

QUESTION 1

A shared resource matrix is a technique commonly used to locate:

- A. Malicious code
- B. Security flaws
- C. Trap doors
- D. Covert channels

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Analyzing resources of a system is one standard for locating covert channels because the basis of a covert channel is a shared resource.

The following properties must hold for a storage channel to exist:

1. Both sending and receiving process must have access to the same attribute of a shared object.
2. The sending process must be able to modify the attribute of the shared object.
3. The receiving process must be able to reference that attribute of the shared object.
4. A mechanism for initiating both processes and properly sequencing their respective accesses to the shared resource must exist.

Note: Similar properties for timing channel can be listed

The following answers are incorrect:

All other answers were not directly related to discovery of Covert Channels. Acerbic Publications, Acerbic Publications (Test Series) - CRC Press LLC, Page No. 225 <http://www.cs.ucsb.edu/~sherwood/cs290/papers/covert-kemmerer.pdf> <http://www.cs.utexas.edu/~byoung/cs361/lecture16.pdf>

QUESTION 2

You are part of a security staff at a highly profitable bank and each day, all traffic on the network is logged for later review. Every Friday when major deposits are made you're seeing a series of bits placed in the "Urgent Pointer" field of a TCP packet. This is only 16 bits which isn't much but it concerns you because:

- A. This could be a sign of covert channeling in bank network communications and should be investigated.
- B. It could be a sign of a damaged network cable causing the issue.
- C. It could be a symptom of malfunctioning network card or drivers and the source system should be checked for the problem.
- D. It is normal traffic because sometimes the previous fields 16-bit checksum value can over run into the urgent pointer's 16-bit field causing the condition.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

The Urgent Pointer is used when some information has to reach the server ASAP. When the TCP/IP stack at the other end sees a packet using the Urgent Pointer set, it is duty bound to stop all ongoing activities and immediately send this packet up the stack for immediate processing. Since the packet is plucked out of the processing queue and acted upon immediately, it is known as an Out Of Band (OOB) packet and the data is called Out Of Band (OOB) data.

The Urgent Pointer is usually used in Telnet, where an immediate response (e.g. the echoing of characters) is desirable.

Covert Channels are not directly synonymous with backdoors. A covert channel is simply using a communication protocol in a way it was not intended to be used or sending data without going through the proper access control mechanisms or channels. For example, in a Mandatory Access Control systems a user at secret has found a way to communicate information to a user at Confidential without going through the normal channels.

In this case the Urgent bit could be used for a few reasons:

1. It could be to attempt a Denial of service where the host receiving a packet with the Urgent bit set will give immediate attention to the request and will be in wait state until the urgent message is received, if the sender does not send the urgent message then it will simply sit there doing nothing until it times out. Some of the TCP/IP stacks used to have a 600 seconds time out, which means that for 10 minutes nobody could use the port. By sending thousands of packet with the URGENT flag set, it would create a very effective denial of service attack.
2. It could be used as a client server application to transmit data back and forward without going through the proper channels. It would be slow but it is possible to use reserved fields and bits to transmit data outside the normal communication channels.

The other answers are incorrect

<http://www.fas.org/irp/nsa/rainbow/tg030.htm> document covering the subject of covert channels and also see: <http://gray-world.net/papers.shtml> which is a large collection of documents on Covert Channels

QUESTION 3

John is the product manager for an information system. His product has undergone under security review by an IS auditor. John has decided to apply appropriate security controls to reduce the security risks suggested

by an IS auditor. Which of the following technique is used by John to treat the identified risk provided by an IS auditor?

- A. Risk Mitigation
- B. Risk Acceptance
- C. Risk Avoidance
- D. Risk transfer

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Risk mitigation is the practice of the elimination of, or the significant decrease in the level of risk presented.

For your exam you should know below information about risk assessment and treatment:

A risk assessment, which is a tool for risk management, is a method of identifying vulnerabilities and threats and assessing the possible impacts to determine where to implement security controls. A risk assessment is carried out, and the results are analyzed. Risk analysis is used to ensure that security is cost-effective, relevant, timely, and responsive to threats. Security can be quite complex, even for well-versed security professionals, and it is easy to apply too much security, not enough security, or the wrong security controls, and to spend too much money in the process without attaining the necessary objectives. Risk analysis helps

companies prioritize their risks and shows management the amount of resources that should be applied to protecting against those risks in a sensible manner.

A risk analysis has four main goals:

Identify assets and their value to the organization.

Identify vulnerabilities and threats.

Quantify the probability and business impact of these potential threats. Provide an economic balance between the impact of the threat and the cost of the countermeasure.

Treating Risk

Risk Mitigation

Risk mitigation is the practice of the elimination of, or the significant decrease in the level of risk presented. Examples of risk mitigation can be seen in everyday life and are readily apparent in the information technology world. Risk Mitigation involves applying appropriate control to reduce risk. For example, to lessen the risk of exposing personal and financial information that is highly sensitive and confidential organizations put countermeasures in place, such as firewalls, intrusion detection/prevention systems, and other mechanisms, to deter malicious outsiders from accessing this highly sensitive information. In the underage driver example, risk mitigation could take the form of driver education for the youth or establishing a policy not allowing the young driver to use a cell phone while driving, or not letting youth of a certain age have more than one friend in the car as a passenger at any given time.

Risk Transfer

Risk transfer is the practice of passing on the risk in question to another entity, such as an insurance company. Let us look at one of the examples that were presented above in a different way. The family is evaluating whether to permit an underage driver to use the family car. The family decides that it is important for the youth to be mobile, so it transfers the financial risk of a youth being in an accident to the insurance company, which provides the family with auto insurance. It is important to note that the transfer of risk may be accompanied by a cost. This is certainly true for the insurance example presented earlier, and can be seen in other insurance instances, such as liability insurance for a vendor or the insurance taken out by companies to protect against hardware and software theft or destruction. This may also be true if an organization must purchase and implement security controls in order to make their organization less desirable to attack. It is important to remember that not all risk can be transferred. While financial risk is simple to transfer through insurance, reputational risk may almost never be fully transferred.

Risk Avoidance

Risk avoidance is the practice of coming up with alternatives so that the risk in question is not realized. For example, have you ever heard a friend, or parents of a friend, complain about the costs of insuring an underage driver? How about the risks that many of these children face as they become mobile? Some of these families will decide that the child in question will not be allowed to drive the family car, but will rather wait until he or she is of legal age (i.e., 18 years of age) before committing to owning, insuring, and driving a motor vehicle. In this case, the family has chosen to avoid the risks (and any associated benefits) associated with an underage driver, such as poor driving performance or the cost of insurance for the child. Although this choice may be available for some situations, it is not available for all. Imagine a global retailer who, knowing the risks associated with doing business on the Internet, decides to avoid the practice. This decision will likely cost the company a significant amount of its revenue (if, indeed, the company has products or services that consumers wish to purchase). In addition, the decision may require the company to build or lease a site in each of the locations, globally, for which it wishes to continue business. This could have a catastrophic effect on the company's ability to continue business operations

Risk Acceptance

In some cases, it may be prudent for an organization to simply accept the risk that is presented in certain scenarios. Risk acceptance is the practice of accepting certain risk(s), typically based on a business decision that may also weigh the cost versus the benefit of dealing with the risk in another way. For example, an executive may be confronted with risks identified during the course of a risk assessment for their organization. These risks have been prioritized by high, medium, and low impact to the organization. The executive notes that in order to mitigate or transfer the low-level risks, significant costs could be involved. Mitigation might involve the hiring of additional highly skilled personnel and the purchase of new hardware, software, and office equipment, while transference of the risk to an insurance company would require premium payments. The executive then further notes that minimal impact to the organization would occur if any of the reported low-level threats were realized. Therefore, he or she (rightly) concludes that it is wiser for the organization to forgo the costs and accept the risk. In the young driver example, risk acceptance could be based on the observation that the youngster has demonstrated the responsibility and maturity to warrant the parent's trust in his or her judgment.

The following answers are incorrect:

Risk Transfer - Risk transfer is the practice of passing on the risk in question to another entity, such as an insurance company. Let us look at one of the examples that were presented above in a different way.

Risk Avoidance - Risk avoidance is the practice of coming up with alternatives so that the risk in question is not realized.

Risk Acceptance - Risk acceptance is the practice of accepting certain risk(s), typically based on a business decision that may also weigh the cost versus the benefit of dealing with the risk in another way.

CISA Review Manual 2014 Page number 51

Official ISC2 guide to CISSP CBK 3rd edition page number 383,384 and 385

QUESTION 4

Sam is the security Manager of a financial institute. Senior management has requested he performs a risk analysis on all critical vulnerabilities reported by an IS auditor. After completing the risk analysis, Sam has observed that for a few of the risks, the cost benefit analysis shows that risk mitigation cost (countermeasures, controls, or safeguard) is more than the potential lost that could be incurred. What kind of a strategy should Sam recommend to the senior management to treat these risks?

- A. Risk Mitigation
- B. Risk Acceptance
- C. Risk Avoidance
- D. Risk transfer

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Risk acceptance is the practice of accepting certain risk(s), typically based on a business decision that may also weigh the cost versus the benefit of dealing with the risk in another way.

For your exam you should know below information about risk assessment and treatment:

A risk assessment, which is a tool for risk management, is a method of identifying vulnerabilities and threats and assessing the possible impacts to determine where to implement security controls. A risk assessment is carried out, and the results are analyzed. Risk analysis is used to ensure that security is cost-effective, relevant, timely, and responsive to threats. Security can be quite complex, even for well-versed security professionals, and it is easy to apply too much security, not enough security, or the wrong security controls, and to spend too much money in the process without attaining the necessary objectives. Risk analysis helps companies prioritize their risks and shows management the amount of resources that should be applied to protecting against those risks in a sensible manner.

A risk analysis has four main goals:

Identify assets and their value to the organization.

Identify vulnerabilities and threats.

Quantify the probability and business impact of these potential threats. Provide an economic balance between the impact of the threat and the cost of the countermeasure.

Treating Risk

Risk Mitigation

Risk mitigation is the practice of the elimination of, or the significant decrease in the level of risk presented. Examples of risk mitigation can be seen in everyday life and are readily apparent in the information technology world. Risk Mitigation involves applying appropriate control to reduce risk. For example, to lessen the risk of exposing personal and financial information that is highly sensitive and confidential organizations put countermeasures in place, such as firewalls, intrusion detection/prevention systems, and other mechanisms, to deter malicious outsiders from accessing this highly sensitive information. In the underage driver example, risk mitigation could take the form of driver education for the youth or establishing a policy not allowing the young driver to use a cell phone while driving, or not letting youth of a certain age have more than one friend in the car as a passenger at any given time.

Risk Transfer

Risk transfer is the practice of passing on the risk in question to another entity, such as an insurance company. Let us look at one of the examples that were presented above in a different way. The family is evaluating whether to permit an underage driver to use the family car. The family decides that it is important for the youth to be mobile, so it transfers the financial risk of a youth being in an accident to the insurance company, which provides the family with auto insurance. It is important to note that the transfer of risk may be accompanied by a cost. This is certainly true for the insurance example presented earlier, and can be seen in other insurance instances, such as liability insurance for a vendor or the insurance taken out by companies to protect against hardware and software theft or destruction. This may also be true if an organization must purchase and implement security controls in order to make their organization less desirable to attack. It is important to remember that not all risk can be transferred. While financial risk is simple to transfer through insurance, reputational risk may almost never be fully transferred.

Risk Avoidance

Risk avoidance is the practice of coming up with alternatives so that the risk in question is not realized. For example, have you ever heard a friend, or parents of a friend, complain about the costs of insuring an underage driver? How about the risks that many of these children face as they become mobile? Some of these families will decide that the child in question will not be allowed to drive the family car, but will rather wait until he or she is of legal age (i.e., 18 years of age) before committing to owning, insuring, and driving a motor vehicle.

In this case, the family has chosen to avoid the risks (and any associated benefits) associated with an underage driver, such as poor driving performance or the cost of insurance for the child. Although this choice may be available for some situations, it is not available for all. Imagine a global retailer who, knowing the risks associated with doing business on the Internet, decides to avoid the practice. This decision will likely cost the company a significant amount of its revenue (if, indeed, the company has products or services that consumers wish to purchase). In addition, the decision may require the company to build or lease a site in each of the locations, globally, for which it wishes to continue business. This could have a catastrophic effect on the company's ability to continue business operations

Risk Acceptance

In some cases, it may be prudent for an organization to simply accept the risk that is presented in certain scenarios. Risk acceptance is the practice of accepting certain risk(s), typically based on a business decision that may also weigh the cost versus the benefit of dealing with the risk in another way. For example, an executive may be confronted with risks identified during the course of a risk assessment for their organization. These risks have been prioritized by high, medium, and low impact to the organization. The executive notes that in order to mitigate or transfer the low-level risks, significant costs could be involved. Mitigation might involve the hiring of additional highly skilled personnel and the purchase of new hardware, software, and office equipment, while transference of the risk to an insurance company would require premium payments. The executive then further notes that minimal impact to the organization would occur if any of the reported low-level threats were realized. Therefore, he or she (rightly) concludes that it is wiser for the organization to forgo the costs and accept the risk. In the young driver example, risk acceptance could be based on the observation that the youngster has demonstrated the responsibility and maturity to warrant the parent's trust in his or her judgment.

The following answers are incorrect:

Risk Transfer - Risk transfer is the practice of passing on the risk in question to another entity, such as an insurance company. Let us look at one of the examples that were presented above in a different way.

Risk Avoidance - Risk avoidance is the practice of coming up with alternatives so that the risk in question is not realized.

Risk Mitigation -Risk mitigation is the practice of the elimination of, or the significant decrease in the level of risk presented.
CISA Review Manual 2014 Page number 51

and
Official ISC2 guide to CISSP CBK 3rd edition page number 534-539

QUESTION 5

Which of the following risk handling technique involves the practice of being proactive so that the risk in question is not realized?

- A. Risk Mitigation
- B. Risk Acceptance
- C. Risk Avoidance
- D. Risk transfer

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Risk avoidance is the practice of coming up with alternatives so that the risk in question is not realized.

For your exam you should know below information about risk assessment and treatment:

A risk assessment, which is a tool for risk management, is a method of identifying vulnerabilities and threats and assessing the possible impacts to determine where to implement security controls. A risk assessment is carried out, and the results are analyzed. Risk analysis is used to ensure that security is cost-effective, relevant, timely, and responsive to threats. Security can be quite complex, even for well-versed security professionals, and it is easy to apply too much security, not enough security, or the wrong security controls, and to spend too much money in the process without attaining the necessary objectives. Risk analysis helps companies prioritize their risks and shows management the amount of resources that should be applied to protecting against those risks in a sensible manner.

A risk analysis has four main goals:

Identify assets and their value to the organization.

Identify vulnerabilities and threats.

Quantify the probability and business impact of these potential threats. Provide an economic balance between the impact of the threat and the cost of the countermeasure.

Treating Risk

Risk Mitigation

Risk mitigation is the practice of the elimination of, or the significant decrease in the level of risk presented. Examples of risk mitigation can be seen in everyday life and are readily apparent in the information technology world. Risk Mitigation involves applying appropriate control to reduce risk. For example, to lessen the risk of exposing personal and financial information that is highly sensitive and confidential organizations put countermeasures in place, such as firewalls, intrusion detection/prevention systems, and other mechanisms, to deter malicious outsiders from accessing this highly sensitive information. In the underage driver example, risk mitigation could take the form of driver education for the youth or establishing a policy not allowing the young driver to use a cell phone while driving,

or not letting youth of a certain age have more than one friend in the car as a passenger at any given time.

Risk Transfer

Risk transfer is the practice of passing on the risk in question to another entity, such as an insurance company. Let us look at one of the examples that were presented above in a different way. The family is evaluating whether to permit an underage driver to use the family car. The family decides that it is important for the youth to be mobile, so it transfers the financial risk of a youth being in an accident to the insurance company, which provides the family with auto insurance. It is important to note that the transfer of risk may be accompanied by a cost. This is certainly true for the insurance example presented earlier, and can be seen in other insurance instances, such as liability insurance for a vendor or the insurance taken out by companies to protect against hardware and software theft or destruction. This may also be true if an organization must purchase and implement security controls in order to make their organization less desirable to attack. It is important to remember that not all risk can be transferred. While financial risk is simple to transfer through insurance, reputational risk may almost never be fully transferred.

Risk Avoidance

Risk avoidance is the practice of coming up with alternatives so that the risk in question is not realized. For example, have you ever heard a friend, or parents of a friend, complain about the costs of insuring an underage driver? How about the risks that many of these children face as they become mobile? Some of these

families will decide that the child in question will not be allowed to drive the family car, but will rather wait until he or she is of legal age (i.e., 18 years of age) before committing to owning, insuring, and driving a motor vehicle.

In this case, the family has chosen to avoid the risks (and any associated benefits) associated with an underage driver, such as poor driving performance or the cost of insurance for the child. Although this choice may be available for some situations, it is not available for all. Imagine a global retailer who, knowing the risks associated with doing business on the Internet, decides to avoid the practice. This decision will likely cost the company a significant amount of its revenue (if, indeed, the company has products or services that consumers wish to purchase). In addition, the decision may require the company to build or lease a site in each of the locations, globally, for which it wishes to continue business. This could have a catastrophic effect on the company's ability to continue business operations

Risk Acceptance

In some cases, it may be prudent for an organization to simply accept the risk that is presented in certain scenarios. Risk acceptance is the practice of accepting certain risk(s), typically based on a business decision that may also weigh the cost versus the benefit of dealing with the risk in another way. For example, an executive may be confronted with risks identified during the course of a risk assessment for their organization. These risks have been prioritized by high, medium, and low impact to the organization. The executive notes that in order to mitigate or transfer the low-level risks, significant costs could be involved. Mitigation might involve the hiring of additional highly skilled personnel and the purchase of new hardware, software, and office equipment, while transference of the risk to an insurance company would require premium payments. The executive then further notes that minimal impact to the organization would occur if any of the reported low-level threats were realized. Therefore, he or she (rightly) concludes that it is wiser for the organization to forgo the costs and accept the risk. In the young driver example, risk acceptance could be based on the observation that the youngster has demonstrated the responsibility and maturity to warrant the parent's trust in his or her judgment.

The following answers are incorrect:

Risk Transfer - Risk transfer is the practice of passing on the risk in question to another entity, such as an insurance company. Let us look at one of the examples that were presented above in a different way.

Risk Acceptance - Risk acceptance is the practice of accepting certain risk(s), typically based on a business decision that may also weigh the cost versus the benefit of dealing with the risk in another way.

Risk Mitigation - Risk mitigation is the practice of the elimination of, or the significant decrease in the level of risk presented

CISA Review Manual 2014 Page number 51

and

Official ISC2 guide to CISSP CBK 3rd edition page number 534-536

QUESTION 6

Which of the following control is intended to discourage a potential attacker?

- A. Deterrent
- B. Preventive
- C. Corrective
- D. Recovery

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Deterrent Control are intended to discourage a potential attacker

For your exam you should know below information about different security controls

Deterrent Controls

Deterrent Controls are intended to discourage a potential attacker. Access controls act as a deterrent to threats and attacks by the simple fact that the existence of the control is enough to keep some potential attackers from attempting to circumvent the control. This is often because the effort required to circumvent the control is far greater than the potential reward if the attacker is successful, or, conversely, the negative implications of a failed attack (or getting caught) outweigh the benefits of success. For example, by forcing the identification and authentication of a user, service, or application, and all that it implies, the potential for incidents associated with the system is significantly reduced because an attacker will fear association with the incident. If there are no controls for a given access path, the number of incidents and the potential impact become infinite. Controls inherently reduce exposure to risk by applying oversight for a process. This oversight acts as a deterrent, curbing an attacker's appetite in the face of probable repercussions.

The best example of a deterrent control is demonstrated by employees and their propensity to intentionally perform unauthorized functions, leading to unwanted events.

When users begin to understand that by authenticating into a system to perform a function, their activities are logged and monitored, and it reduces the likelihood they will attempt such an action. Many threats are based on the anonymity of the threat agent, and any potential for identification and association with their actions is avoided at all costs.

It is this fundamental reason why access controls are the key target of circumvention by attackers. Deterrents also take the form of potential punishment if users do something unauthorized. For example, if the organization policy specifies that an employee installing an unauthorized wireless access point will be fired, that will determine most employees from installing wireless access points.

Preventative Controls

Preventive controls are intended to avoid an incident from occurring. Preventative access controls keep a user from performing some activity or function.

Preventative controls differ from deterrent controls in that the control is not optional and cannot (easily) be bypassed. Deterrent controls work on the theory that it is easier to obey the control

rather than to risk the consequences of bypassing the control. In other words, the power for action resides with the user (or the attacker). Preventative controls place the power of action with the system, obeying the control is not optional. The only way to bypass the control is to find a flaw in the control's implementation.

Compensating Controls

Compensating controls are introduced when the existing capabilities of a system do not support the requirement of a policy. Compensating controls can be

technical, procedural, or managerial. Although an existing system may not support the required controls, there may exist other technology or processes that can supplement the existing environment, closing the gap in controls, meeting policy requirements, and reducing overall risk.

For example, the access control policy may state that the authentication process must be encrypted when performed over the Internet. Adjusting an application to natively support encryption for authentication purposes may be too costly. Secure Socket Layer (SSL), an encryption protocol, can be employed and layered on top of the authentication process to support the policy statement.

Other examples include a separation of duties environment, which offers the capability to isolate certain tasks to compensate for technical limitations in the system and ensure the security of transactions. In addition, management processes, such as authorization, supervision, and administration, can be used to compensate for gaps in the access control environment.

Detective Controls

Detective controls warn when something has happened, and are the earliest point in the post-incident timeline.

Access controls are a deterrent to threats and can be aggressively utilized to prevent harmful incidents through the application of least privilege. However, the detective nature of access controls can provide significant visibility into the access environment and help organizations manage their access strategy and related security risk.

As mentioned previously, strongly managed access privileges provided to an authenticated user offer the ability to reduce the risk exposure of the enterprise's assets by limiting the capabilities that authenticated user has. However, there are few options to control what a user can perform once privileges are provided. For example, if a user is provided write access to a file and that file is damaged, altered, or otherwise negatively impacted (either deliberately or unintentionally), the use of applied access controls will offer visibility into the transaction. The control environment can be established to log activity regarding the identification, authentication, authorization, and use of privileges on a system.

This can be used to detect the occurrence of errors, the attempts to perform an unauthorized action, or to validate when provided credentials were exercised. The logging system as a detective device provides evidence of actions (both successful and unsuccessful) and tasks that were executed by authorized users.

Corrective Controls

When a security incident occurs, elements within the security infrastructure may require corrective actions. Corrective controls are actions that seek to alter the security posture of an environment to correct any deficiencies and return the environment to a secure state. A security incident signals the failure of one or more directive, deterrent, preventative, or compensating controls. The detective controls may have triggered an alarm or notification, but now the corrective controls must work to stop the incident in its tracks. Corrective controls can take many forms, all depending on the particular situation at hand or the particular security failure that needs to be dealt with.

Recovery Controls

Any changes to the access control environment, whether in the face of a security incident or to offer temporary compensating controls, need to be accurately reinstated and returned to normal operations. There are several situations that may affect access controls, their applicability, status, or management.

Events can include system outages, attacks, project changes, technical demands, administrative gaps, and full-blown disaster situations. For example, if an application is not correctly installed or deployed, it may adversely affect controls placed on system files or even have default administrative accounts unknowingly implemented upon install.

Additionally, an employee may be transferred, quit, or be on temporary leave that may affect policy requirements regarding separation of duties. An attack on systems may have resulted in the implantation of a Trojan horse program, potentially exposing private user information, such as credit card information and financial data. In all of these cases, an undesirable situation must be rectified as quickly as possible and controls returned to normal operations.

The following answers are incorrect:

Preventive - Preventive controls are intended to avoid an incident from occurring
Corrective - Corrective control fixes components or systems after an incident has occurred
Recovery - Recovery controls are intended to bring the environment back to regular operations
CISA Review Manual 2014 Page number 44
and
Official ISC2 CISSP guide 3rd edition Page number 50 and 51

QUESTION 7

Which of the following security control is intended to avoid an incident from occurring?

- A. Deterrent
- B. Preventive
- C. Corrective
- D. Recovery

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Preventive controls are intended to avoid an incident from occurring

For your exam you should know below information about different security controls

Deterrent Controls

Deterrent Controls are intended to discourage a potential attacker. Access controls act as a deterrent to threats and attacks by the simple fact that the existence of the control is enough to keep some potential attackers from attempting to circumvent the control. This is often because the effort required to circumvent the control is far greater than the potential reward if the attacker is successful, or, conversely, the negative implications of a failed attack (or getting caught) outweigh the benefits of success. For example, by forcing the identification and authentication of a user, service, or application, and all that it implies, the potential for incidents associated with the system is significantly reduced because an attacker will fear association with the incident. If there are no controls for a given access path, the number of incidents and the potential impact become infinite. Controls inherently reduce exposure to risk by applying oversight for a process. This oversight acts as a deterrent, curbing an attacker's appetite in the face of probable repercussions.

The best example of a deterrent control is demonstrated by employees and their propensity to intentionally perform unauthorized functions, leading to unwanted events.

When users begin to understand that by authenticating into a system to perform a function, their activities are logged and monitored, and it reduces the likelihood they will attempt such an action. Many threats are based on the anonymity of the threat agent, and any potential for identification and association with their actions is avoided at all costs.

It is this fundamental reason why access controls are the key target of circumvention by attackers. Deterrents also take the form of potential punishment if users do something unauthorized. For example, if the organization policy specifies that an employee installing an unauthorized wireless access point will be fired, that will determine most employees from installing wireless access points.

Preventative Controls

Preventive controls are intended to avoid an incident from occurring. Preventative access controls keep a user from performing some activity or function.

Preventative controls differ from deterrent controls in that the control is not optional and cannot (easily) be bypassed. Deterrent controls work on the theory that it is easier to obey the control

rather than to risk the consequences of bypassing the control. In other words, the power for action resides with the user (or the attacker). Preventative controls place the power of action with the system, obeying the control is not optional. The only way to bypass the control is to find a flaw in the control's implementation.

Compensating Controls

Compensating controls are introduced when the existing capabilities of a system do not support the requirement of a policy. Compensating controls can be technical, procedural, or managerial. Although an existing system may not support the required controls, there may exist other technology or processes that can supplement the existing environment, closing the gap in controls, meeting policy requirements, and reducing overall risk.

For example, the access control policy may state that the authentication process must be encrypted when performed over the Internet. Adjusting an application to natively support encryption for authentication purposes

may be too costly. Secure Socket Layer (SSL), an encryption protocol, can be employed and layered on top of the authentication process to support the policy statement.

Other examples include a separation of duties environment, which offers the capability to isolate certain tasks to compensate for technical limitations in the system and ensure the security of transactions. In addition, management processes, such as authorization, supervision, and administration, can be used to compensate for gaps in the access control environment.

Detective Controls

Detective controls warn when something has happened, and are the earliest point in the post-incident timeline. Access controls are a deterrent to threats and can be aggressively utilized to prevent harmful incidents through the application of least privilege. However, the detective nature of access controls can provide significant visibility into the access environment and help organizations manage their access strategy and related security risk.

As mentioned previously, strongly managed access privileges provided to an authenticated user offer the ability to reduce the risk exposure of the enterprise's assets by limiting the capabilities that authenticated user has. However, there are few options to control what a user can perform once privileges are provided. For example, if a user is provided write access to a file and that file is damaged, altered, or otherwise negatively impacted (either deliberately or unintentionally), the use of applied access controls will offer visibility into the transaction. The control environment can be established to log activity regarding the identification, authentication, authorization, and use of privileges on a system. This can be used to detect the occurrence of errors, the attempts to perform an unauthorized action, or to validate when provided credentials were exercised. The logging system as a detective device provides evidence of actions (both successful and unsuccessful) and tasks that were executed by authorized users.

Corrective Controls

When a security incident occurs, elements within the security infrastructure may require corrective actions. Corrective controls are actions that seek to alter the security posture of an environment to correct any deficiencies and return the environment to a secure state. A security incident signals the failure of one or more directive, deterrent, preventative, or compensating controls. The detective controls may have triggered an alarm or notification, but now the corrective controls must work to stop the incident in its tracks. Corrective controls can take many forms, all depending on the particular situation at hand or the particular security failure that needs to be dealt with.

Recovery Controls

Any changes to the access control environment, whether in the face of a security incident or to offer temporary compensating controls, need to be accurately reinstated and returned to normal operations. There are several situations that may affect access controls, their applicability, status, or management.

Events can include system outages, attacks, project changes, technical demands, administrative gaps, and full-blown disaster situations. For example, if an application is not correctly installed or deployed, it may adversely affect controls placed on system files or even have default administrative accounts unknowingly implemented upon install.

Additionally, an employee may be transferred, quit, or be on temporary leave that may affect policy requirements regarding separation of duties. An attack on systems may have resulted in the implantation of a Trojan horse program, potentially exposing private user information, such as credit card information and financial data. In all of these cases, an undesirable situation must be rectified as quickly as possible and controls returned to normal operations.

The following answers are incorrect:

Deterrent - Deterrent controls are intended to discourage a potential attacker
Recovery - Recovery controls are intended to bring the environment back to regular operations
Corrective - Corrective control fixes components or systems after an incident has occurred
CISA Review Manual 2014 Page number 44
Official ISC2 CISSP guide 3rd edition Page number 50 and 51

QUESTION 8

Which of the following control fixes a component or system after an incident has occurred?

- A. Deterrent
- B. Preventive
- C. Corrective
- D. Recovery

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Corrective control fixes components or systems after an incident has occurred For your exam you should know below information about different security controls

Deterrent Controls

Deterrent Controls are intended to discourage a potential attacker. Access controls act as a deterrent to threats and attacks by the simple fact that the existence of the control is enough to keep some potential attackers from attempting to circumvent the control. This is often because the effort required to circumvent the control is far greater than the potential reward if the attacker is successful, or, conversely, the negative implications of a failed attack (or getting caught) outweigh the benefits of success. For example, by forcing the identification and authentication of a user, service, or application, and all that it implies, the potential for incidents associated with the system is significantly reduced because an attacker will fear association with the incident. If there are no controls for a given access path, the number of incidents and the potential impact become infinite. Controls inherently reduce exposure to risk by applying oversight for a process. This oversight acts as a deterrent, curbing an attacker's appetite in the face of probable repercussions.

The best example of a deterrent control is demonstrated by employees and their propensity to intentionally perform unauthorized functions, leading to unwanted events.

When users begin to understand that by authenticating into a system to perform a function, their activities are logged and monitored, and it reduces the likelihood they will attempt such an action. Many threats are based on the anonymity of the threat agent, and any potential for identification and association with their actions is avoided at all costs.

It is this fundamental reason why access controls are the key target of circumvention by attackers. Deterrents also take the form of potential punishment if users do something unauthorized. For example, if the organization policy specifies that an employee installing an unauthorized wireless access point will be fired, that will determine most employees from installing wireless access points.

Preventative Controls

Preventive controls are intended to avoid an incident from occurring. Preventative access controls keep a user from performing some activity or function.

Preventative controls differ from deterrent controls in that the control is not optional and cannot (easily) be bypassed. Deterrent controls work on the theory that it is easier to obey the control

rather than to risk the consequences of bypassing the control. In other words, the power for action resides with the user (or the attacker). Preventative controls place the power of action with the system, obeying the control is not optional. The only way to bypass the control is to find a flaw in the control's implementation.

Compensating Controls

Compensating controls are introduced when the existing capabilities of a system do not support the requirement of a policy. Compensating controls can be technical, procedural, or managerial. Although an existing system may not support the required controls, there may exist other technology or processes that can supplement the existing environment, closing the gap in controls, meeting policy requirements, and reducing overall risk.

For example, the access control policy may state that the authentication process must be encrypted when performed over the Internet. Adjusting an application to natively support encryption for authentication purposes may be too costly. Secure Socket Layer (SSL), an encryption protocol, can be employed and layered on top of the authentication process to support the policy statement.

Other examples include a separation of duties environment, which offers the capability to isolate certain tasks to compensate for technical limitations in the system and ensure the security of transactions. In addition, management processes, such as authorization, supervision, and administration, can be used to compensate for gaps in the access control environment.

Detective Controls

Detective controls warn when something has happened, and are the earliest point in the post-incident timeline. Access controls are a deterrent to threats and can be aggressively utilized to prevent harmful incidents through the application of least privilege. However, the detective nature of access controls can provide significant visibility into the access environment and help organizations manage their access strategy and related security risk.

As mentioned previously, strongly managed access privileges provided to an authenticated user offer the ability to reduce the risk exposure of the enterprise's assets by limiting the capabilities that authenticated user has. However, there are few options to control what a user can perform once privileges are provided. For example, if a user is provided write access to a file and that file is damaged, altered, or otherwise negatively impacted (either deliberately or unintentionally), the use of applied access controls will offer visibility into the transaction. The control environment can be established to log activity regarding the identification, authentication, authorization, and use of privileges on a system.

This can be used to detect the occurrence of errors, the attempts to perform an unauthorized action, or to validate when provided credentials were exercised. The logging system as a detective device provides evidence of actions (both successful and unsuccessful) and tasks that were executed by authorized users.

Corrective Controls

When a security incident occurs, elements within the security infrastructure may require corrective actions. Corrective controls are actions that seek to alter the security posture of an environment to correct any deficiencies and return the environment to a secure state. A security incident signals the failure of one or more directive, deterrent, preventative, or compensating controls. The detective controls may have triggered an alarm or notification, but now the corrective controls must work to stop the incident in its tracks. Corrective controls can take many forms, all depending on the particular situation at hand or the particular security failure that needs to be dealt with.

Recovery Controls

Any changes to the access control environment, whether in the face of a security incident or to offer temporary compensating controls, need to be accurately reinstated and returned to normal operations. There are several situations that may affect access controls, their applicability, status, or management.

Events can include system outages, attacks, project changes, technical demands, administrative gaps, and full-blown disaster situations. For example, if an application is not correctly installed or deployed, it may adversely affect controls placed on system files or even have default administrative accounts unknowingly implemented upon install.

Additionally, an employee may be transferred, quit, or be on temporary leave that may affect policy requirements regarding separation of duties. An attack on systems may have resulted in the implantation of a Trojan horse program, potentially exposing private user information, such as credit card information and financial data. In all of these cases, an undesirable situation must be rectified as quickly as possible and

controls returned to normal operations.

The following answers are incorrect:

Deterrent - Deterrent controls are intended to discourage a potential attacker

Preventive - Preventive controls are intended to avoid an incident from occurring Recovery - Recovery controls are intended to bring the environment back to regular operations CISA Review Manual 2014 Page number 44 and Official ISC2 CISSP guide 3rd edition Page number 50 and 51.

QUESTION 9

Which of the following security control is intended to bring environment back to regular operation?

- A. Deterrent
- B. Preventive
- C. Corrective
- D. Recovery

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Recovery controls are intended to bring the environment back to regular operations

For your exam you should know below information about different security controls

Deterrent Controls

Deterrent Controls are intended to discourage a potential attacker. Access controls act as a deterrent to threats and attacks by the simple fact that the existence of the control is enough to keep some potential attackers from attempting to circumvent the control. This is often because the effort required to circumvent the control is far greater than the potential reward if the attacker is successful, or, conversely, the negative implications of a failed attack (or getting caught) outweigh the benefits of success. For example, by forcing the identification and authentication of a user, service, or application, and all that it implies, the potential for incidents associated with the system is significantly reduced because an attacker will fear association with the incident. If there are no controls for a given access path, the number of incidents and the potential impact become infinite. Controls inherently reduce exposure to risk by applying oversight for a process. This oversight acts as a deterrent, curbing an attacker's appetite in the face of probable repercussions.

The best example of a deterrent control is demonstrated by employees and their propensity to intentionally perform unauthorized functions, leading to unwanted events.

When users begin to understand that by authenticating into a system to perform a function, their activities are logged and monitored, and it reduces the likelihood they will attempt such an action. Many threats are based on the anonymity of the threat agent, and any potential for identification and association with their actions is avoided at all costs.

It is this fundamental reason why access controls are the key target of circumvention by attackers. Deterrents also take the form of potential punishment if users do something unauthorized. For example, if the organization policy specifies that an employee installing an unauthorized wireless access point will be fired, that will

determine most employees from installing wireless access points.

Preventative Controls

Preventive controls are intended to avoid an incident from occurring. Preventative access controls keep a user from performing some activity or function. Preventative controls differ from deterrent controls in that the control is not optional and cannot (easily) be bypassed. Deterrent controls work on the theory that it is easier to obey the control rather than to risk the consequences of bypassing the control. In other words, the power for action resides with the user (or the attacker). Preventative controls place the power of action with the system, obeying the control is not optional. The only way to bypass the control is to find a flaw in the control's implementation.

Compensating Controls

Compensating controls are introduced when the existing capabilities of a system do not support the requirement of a policy. Compensating controls can be technical, procedural, or managerial. Although an existing system may not support the required controls, there may exist other technology or processes that can supplement the existing environment, closing the gap in controls, meeting policy requirements, and reducing overall risk.

For example, the access control policy may state that the authentication process must be encrypted when performed over the Internet. Adjusting an application to natively support encryption for authentication purposes may be too costly. Secure Socket Layer (SSL), an encryption protocol, can be employed and layered on top of the authentication process to support the policy statement. Other examples include a separation of duties environment, which offers the capability to isolate certain tasks to compensate for technical limitations in the system and ensure the security of transactions. In addition, management processes, such as authorization, supervision, and administration, can be used to compensate for gaps in the access control environment.

Detective Controls

Detective controls warn when something has happened, and are the earliest point in the post-incident timeline. Access controls are a deterrent to threats and can be aggressively utilized to prevent harmful incidents through the application of least privilege. However, the detective nature of access controls can provide significant visibility into the access environment and help organizations manage their access strategy and related security risk.

As mentioned previously, strongly managed access privileges provided to an authenticated user offer the ability to reduce the risk exposure of the enterprise's assets by limiting the capabilities that authenticated user has. However, there are few options to control what a user can perform once privileges are provided. For example, if a user is provided write access to a file and that file is damaged, altered, or otherwise negatively impacted (either deliberately or unintentionally), the use of applied access controls will offer visibility into the transaction. The control environment can be established to log activity regarding the identification, authentication, authorization, and use of privileges on a system.

This can be used to detect the occurrence of errors, the attempts to perform an unauthorized action, or to validate when provided credentials were exercised. The logging system as a detective device provides evidence of actions (both successful and unsuccessful) and tasks that were executed by authorized users.

Corrective Controls

When a security incident occurs, elements within the security infrastructure may require corrective actions. Corrective controls are actions that seek to alter the security posture of an environment to correct any deficiencies and return the environment to a secure state. A security incident signals the failure of one or more directive, deterrent, preventative, or compensating controls. The detective controls may have triggered an alarm or notification, but now the corrective controls must work to stop the incident in its tracks. Corrective controls can take many forms, all depending on the particular situation at hand or the particular security failure that needs to be dealt with.

Recovery Controls

Any changes to the access control environment, whether in the face of a security incident or to offer temporary compensating controls, need to be accurately reinstated and returned to normal operations. There are several

situations that may affect access controls, their applicability, status, or management.

Events can include system outages, attacks, project changes, technical demands, administrative gaps, and full-blown disaster situations. For example, if an application is not correctly installed or deployed, it may adversely affect controls placed on system files or even have default administrative accounts unknowingly implemented upon install.

Additionally, an employee may be transferred, quit, or be on temporary leave that may affect policy requirements regarding separation of duties. An attack on systems may have resulted in the implantation of a Trojan horse program, potentially exposing private user information, such as credit card information and financial data. In all of these cases, an undesirable situation must be rectified as quickly as possible and controls returned to normal operations.

The following answers are incorrect:

Deterrent - Deterrent controls are intended to discourage a potential attacker

Preventive - Preventive controls are intended to avoid an incident from occurring

Corrective - Corrective control fixes components or systems after an incident has occurred CISA Review Manual 2014 Page number 44 and
Official ISC2 CISSP guide 3rd edition Page number 50 and 51

QUESTION 10

Which of the following control helps to identify an incident's activities and potentially an intruder?

- A. Deterrent
- B. Preventive
- C. Detective
- D. Compensating

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Detective control helps identify an incident's activities and potentially an intruder

For your exam you should know below information about different security controls

Deterrent Controls

Deterrent Controls are intended to discourage a potential attacker. Access controls act as a deterrent to threats and attacks by the simple fact that the existence of the control is enough to keep some potential attackers from attempting to circumvent the control. This is often because the effort required to circumvent the control is far greater than the potential reward if the attacker is successful, or, conversely, the negative implications of a failed attack (or getting caught) outweigh the benefits of success. For example, by forcing the identification and authentication of a user, service, or application, and all that it implies, the potential for incidents associated with the system is significantly reduced because an attacker will fear association with the incident. If there are no controls for a given access path, the

number of incidents and the potential impact become infinite. Controls inherently reduce exposure to risk by applying oversight for a process. This oversight acts as a deterrent, curbing an attacker's appetite in the face of probable repercussions.

The best example of a deterrent control is demonstrated by employees and their propensity to intentionally perform unauthorized functions, leading to unwanted events.

When users begin to understand that by authenticating into a system to perform a function, their activities are logged and monitored, and it reduces the likelihood they will attempt such an action. Many threats are based on the anonymity of the threat agent, and any potential for identification and association with their actions is avoided at all costs.

It is this fundamental reason why access controls are the key target of circumvention by attackers. Deterrents also take the form of potential punishment if users do something unauthorized. For example, if the organization policy specifies that an employee installing an unauthorized wireless access point will be fired, that will determine most employees from installing wireless access points.

Preventative Controls

Preventive controls are intended to avoid an incident from occurring. Preventative access controls keep a user from performing some activity or function.

Preventative controls differ from deterrent controls in that the control is not optional and cannot (easily) be bypassed. Deterrent controls work on the theory that it is easier to obey the control

rather than to risk the consequences of bypassing the control. In other words, the power for action resides with the user (or the attacker). Preventative controls place the power of action with the system, obeying the control is not optional. The only way to bypass the control is to find a flaw in the control's implementation.

Compensating Controls

Compensating controls are introduced when the existing capabilities of a system do not support the requirement of a policy. Compensating controls can be technical, procedural, or managerial. Although an existing system may not support the required controls, there may exist other technology or processes that can supplement the existing environment, closing the gap in controls, meeting policy requirements, and reducing overall risk.

For example, the access control policy may state that the authentication process must be encrypted when performed over the Internet. Adjusting an application to natively support encryption for authentication purposes may be too costly. Secure Socket Layer (SSL), an encryption protocol, can be employed and layered on top of the authentication process to support the policy statement.

Other examples include a separation of duties environment, which offers the capability to isolate certain tasks to compensate for technical limitations in the system and ensure the security of transactions. In addition, management processes, such as authorization, supervision, and administration, can be used to compensate for gaps in the access control environment.

Detective Controls

Detective controls warn when something has happened, and are the earliest point in the post-incident timeline. Access controls are a deterrent to threats and can be aggressively utilized to prevent harmful incidents through the application of least privilege. However, the detective nature of access controls can provide significant visibility into the access environment and help organizations manage their access strategy and related security risk.

As mentioned previously, strongly managed access privileges provided to an authenticated user offer the ability to reduce the risk exposure of the enterprise's assets by limiting the capabilities that authenticated user has. However, there are few options to control what a user can perform once privileges are provided. For example, if a user is provided write access to a file and that file is damaged, altered, or otherwise negatively impacted (either deliberately or unintentionally), the use of applied access controls will offer visibility into the transaction. The control environment can be established to log activity regarding the identification, authentication, authorization, and use of privileges on a system.

This can be used to detect the occurrence of errors, the attempts to perform an unauthorized action, or to validate when provided credentials were exercised. The logging system as a detective device provides evidence of actions (both successful and unsuccessful) and tasks that were executed by authorized users.

Corrective Controls

When a security incident occurs, elements within the security infrastructure may require corrective actions. Corrective controls are actions that seek to alter the security posture of an environment to correct any deficiencies and return the environment to a secure state. A security incident signals the failure of one or more directive, deterrent, preventative, or compensating controls. The detective controls may have triggered an alarm or notification, but now the corrective controls must work to stop the incident in its tracks. Corrective controls can take many forms, all depending on the particular situation at hand or the particular security failure that needs to be dealt with.

Recovery Controls

Any changes to the access control environment, whether in the face of a security incident or to offer temporary compensating controls, need to be accurately reinstated and returned to normal operations. There are several situations that may affect access controls, their applicability, status, or management.

Events can include system outages, attacks, project changes, technical demands, administrative gaps, and full-blown disaster situations. For example, if an application is not correctly installed or deployed, it may adversely affect controls placed on system files or even have default administrative accounts unknowingly implemented upon install.

Additionally, an employee may be transferred, quit, or be on temporary leave that may affect policy requirements regarding separation of duties. An attack on systems may have resulted in the implantation of a Trojan horse program, potentially exposing private user information, such as credit card information and financial data. In all of these cases, an undesirable situation must be rectified as quickly as possible and controls returned to normal operations.

The following answers are incorrect:

Deterrent - Deterrent controls are intended to discourage a potential attacker
Preventive - Preventive controls are intended to avoid an incident from occurring
Compensating - Compensating Controls provide an alternative measure of control
CISA Review Manual 2014 Page number 44
and
Official ISC2 CISSP guide 3rd edition Page number 50 and 51

QUESTION 11

Which of the following control provides an alternative measure of control?

- A. Deterrent
- B. Preventive
- C. Detective
- D. Compensating

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

For your exam you should know below information about different security controls

Deterrent Controls

Deterrent Controls are intended to discourage a potential attacker. Access controls act as a deterrent to threats and attacks by the simple fact that the existence of the control is enough to keep some potential

attackers from attempting to circumvent the control. This is often because the effort required to circumvent the control is far greater than the potential reward if the attacker is successful, or, conversely, the negative implications of a failed attack (or getting caught) outweigh the benefits of success. For example, by forcing the

identification and authentication of a user, service, or application, and all that it implies, the potential for incidents associated with the system is significantly reduced because an attacker will fear association with the incident. If there are no controls for a given access path, the number of incidents and the potential impact become infinite. Controls inherently reduce exposure to risk by applying oversight for a process. This oversight acts as a deterrent, curbing an attacker's appetite in the face of probable repercussions. The best example of a deterrent control is demonstrated by employees and their propensity to intentionally perform unauthorized functions, leading to unwanted events. When users begin to understand that by authenticating into a system to perform a function, their activities are logged and monitored, and it reduces the likelihood they will attempt such an action. Many threats are based on the anonymity of the threat agent, and any potential for identification and association with their actions is avoided at all costs. It is this fundamental reason why access controls are the key target of circumvention by attackers. Deterrents also take the form of potential punishment if users do something unauthorized. For example, if the organization policy specifies that an employee installing an unauthorized wireless access point will be fired, that will determine most employees from installing wireless access points.

Preventative Controls

Preventive controls are intended to avoid an incident from occurring. Preventative access controls keep a user from performing some activity or function. Preventative controls differ from deterrent controls in that the control is not optional and cannot (easily) be bypassed. Deterrent controls work on the theory that it is easier to obey the control rather than to risk the consequences of bypassing the control. In other words, the power for action resides with the user (or the attacker). Preventative controls place the power of action with the system, obeying the control is not optional. The only way to bypass the control is to find a flaw in the control's implementation.

Compensating Controls

Compensating controls are introduced when the existing capabilities of a system do not support the requirement of a policy. Compensating controls can be technical, procedural, or managerial. Although an existing system may not support the required controls, there may exist other technology or processes that can supplement the existing environment, closing the gap in controls, meeting policy requirements, and reducing overall risk. For example, the access control policy may state that the authentication process must be encrypted when performed over the Internet. Adjusting an application to natively support encryption for authentication purposes may be too costly. Secure Socket Layer (SSL), an encryption protocol, can be employed and layered on top of the authentication process to support the policy statement. Other examples include a separation of duties environment, which offers the capability to isolate certain tasks to compensate for technical limitations in the system and ensure the security of transactions. In addition, management processes, such as authorization, supervision, and administration, can be used to compensate for gaps in the access control environment.

Detective Controls

Detective controls warn when something has happened, and are the earliest point in the post-incident timeline. Access controls are a deterrent to threats and can be aggressively utilized to prevent harmful incidents through the application of least privilege. However, the detective nature of access controls can provide significant visibility into the access environment and help organizations manage their access strategy and related security risk. As mentioned previously, strongly managed access privileges provided to an authenticated user offer the ability to reduce the risk exposure of the enterprise's assets by limiting the capabilities that authenticated user has. However, there are few options to control what a user can perform once privileges are provided. For example, if a user is provided write access to a file and that file is damaged, altered, or otherwise negatively impacted (either deliberately or unintentionally), the use of applied access controls will offer visibility into the transaction. The control environment can be established to log activity regarding the identification, authentication, authorization, and use of privileges on a system. This can be used to detect the occurrence of errors, the attempts to perform an unauthorized action, or to validate when provided credentials were exercised. The logging system as a detective device provides evidence of actions (both successful and unsuccessful) and tasks that were executed by authorized users.

Corrective Controls

When a security incident occurs, elements within the security infrastructure may require corrective actions. Corrective controls are actions that seek to alter the security posture of an environment to correct any deficiencies and return the environment to a secure state. A security incident signals the failure of one or more directive, deterrent, preventative, or compensating controls. The detective controls may have triggered an alarm or notification, but now the corrective controls must work to stop the incident in its tracks. Corrective controls can take many forms, all depending on the particular situation at hand or the particular security failure that needs to be dealt with.

Recovery Controls

Any changes to the access control environment, whether in the face of a security incident or to offer temporary compensating controls, need to be accurately reinstated and returned to normal operations. There are several situations that may affect access controls, their applicability, status, or management. Events can include system outages, attacks, project changes, technical demands, administrative gaps, and full-blown disaster situations. For example, if an application is not correctly installed or deployed, it may adversely affect controls placed on system files or even have default administrative accounts unknowingly implemented upon install. Additionally, an employee may be transferred, quit, or be on temporary leave that may affect policy requirements regarding separation of duties. An attack on systems may have resulted in the implantation of a Trojan horse program, potentially exposing private user information, such as credit card information and financial data. In all of these cases, an undesirable situation must be rectified as quickly as possible and controls returned to normal operations. For your exam you should know below information about different security controls

Deterrent Controls

Deterrent Controls are intended to discourage a potential attacker. Access controls act as a deterrent to threats and attacks by the simple fact that the existence of the control is enough to keep some potential attackers from attempting to circumvent the control. This is often because the effort required to circumvent the control is far greater than the potential reward if the attacker is successful, or, conversely, the negative implications of a failed attack (or getting caught) outweigh the benefits of success. For example, by forcing the identification and authentication of a user, service, or application, and all that it implies, the potential for incidents associated with the system is significantly reduced because an attacker will fear association with the incident. If there are no controls for a given access path, the number of incidents and the potential impact become infinite. Controls inherently reduce exposure to risk by applying oversight for a process. This oversight acts as a deterrent, curbing an attacker's appetite in the face of probable repercussions.

The best example of a deterrent control is demonstrated by employees and their propensity to intentionally perform unauthorized functions, leading to unwanted events.

When users begin to understand that by authenticating into a system to perform a function, their activities are logged and monitored, and it reduces the likelihood they will attempt such an action. Many threats are based on the anonymity of the threat agent, and any potential for identification and association with their actions is avoided at all costs.

It is this fundamental reason why access controls are the key target of circumvention by attackers. Deterrents also take the form of potential punishment if users do something unauthorized. For example, if the organization policy specifies that an employee installing an unauthorized wireless access point will be fired, that will determine most employees from installing wireless access points.

Preventative Controls

Preventive controls are intended to avoid an incident from occurring. Preventative access controls keep a user from performing some activity or function. Preventative controls differ from deterrent controls in that the control is not optional and cannot (easily) be bypassed. Deterrent controls work on the theory that it is easier to obey the control rather than to risk the consequences of bypassing the control. In other words, the power for action resides with the user (or the attacker). Preventative controls place the power of action with the system, obeying the control is not optional. The only way to bypass the control is to find a flaw in the control's implementation.

Compensating Controls

Compensating controls are introduced when the existing capabilities of a system do not support the requirement of a policy. Compensating controls can be technical, procedural, or managerial. Although an existing system may not support the required controls, there may exist other technology or processes that can supplement the existing environment, closing the gap in controls, meeting policy requirements, and reducing overall risk.

For example, the access control policy may state that the authentication process must be encrypted when performed over the Internet. Adjusting an application to natively support encryption for authentication purposes may be too costly. Secure Socket Layer (SSL), an encryption protocol, can be employed and layered on top of the authentication process to support the policy statement.

Other examples include a separation of duties environment, which offers the capability to isolate certain tasks to compensate for technical limitations in the system and ensure the security of transactions. In addition, management processes, such as authorization, supervision, and administration, can be used to compensate for gaps in the access control environment.

Detective Controls

Detective controls warn when something has happened, and are the earliest point in the post-incident timeline. Access controls are a deterrent to threats and can be aggressively utilized to prevent harmful incidents through the application of least privilege. However, the detective nature of access controls can provide significant visibility into the access environment and help organizations manage their access strategy and related security risk.

As mentioned previously, strongly managed access privileges provided to an authenticated user offer the ability to reduce the risk exposure of the enterprise's assets by limiting the capabilities that authenticated user has. However, there are few options to control what a user can perform once privileges are provided. For example, if a user is provided write access to a file and that file is damaged, altered, or otherwise negatively impacted (either deliberately or unintentionally), the use of applied access controls will offer visibility into the transaction. The control environment can be established to log activity regarding the identification, authentication, authorization, and use of privileges on a system.

This can be used to detect the occurrence of errors, the attempts to perform an unauthorized action, or to validate when provided credentials were exercised. The logging system as a detective device provides evidence of actions (both successful and unsuccessful) and tasks that were executed by authorized users.

Corrective Controls

When a security incident occurs, elements within the security infrastructure may require corrective actions. Corrective controls are actions that seek to alter the security posture of an environment to correct any deficiencies and return the environment to a secure state. A security incident signals the failure of one or more directive, deterrent, preventative, or compensating controls. The detective controls may have triggered an alarm or notification, but now the corrective controls must work to stop the incident in its tracks. Corrective controls can take many forms, all depending on the particular situation at hand or the particular security failure that needs to be dealt with.

Recovery Controls

Any changes to the access control environment, whether in the face of a security incident or to offer temporary compensating controls, need to be accurately reinstated and returned to normal operations. There are several situations that may affect access controls, their applicability, status, or management.

Events can include system outages, attacks, project changes, technical demands, administrative gaps, and full-blown disaster situations. For example, if an application is not correctly installed or deployed, it may adversely affect controls placed on system files or even have default administrative accounts unknowingly implemented upon install.

Additionally, an employee may be transferred, quit, or be on temporary leave that may affect policy requirements regarding separation of duties. An attack on systems may have resulted in the implantation of a Trojan horse program, potentially exposing private user information, such as credit card information and financial data. In all of these cases, an undesirable situation must be rectified as quickly as possible and controls returned to normal operations.

The following answers are incorrect:

Deterrent - Deterrent controls are intended to discourage a potential attacker Preventive - Preventive controls are intended to avoid an incident from occurring
Detective - Detective control helps identify an incident's activities and potentially an intruder CISA Review Manual 2014 Page number 44
and
Official ISC2 CISSP guide 3rd edition Page number 50 and 51

QUESTION 12

Which of the following is NOT an example of preventive control?

- A. Physical access control like locks and door
- B. User login screen which allows only authorize user to access website
- C. Encrypt the data so that only authorize user can view the same
- D. Duplicate checking of a calculations

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

The word NOT is used as a keyword in the question. You need to find out a security control from given options which is not preventive. Duplicate checking of a calculation is a detective control and not a preventive control.

For your exam you should know below information about different security controls

Deterrent Controls

Deterrent Controls are intended to discourage a potential attacker. Access controls act as a deterrent to threats and attacks by the simple fact that the existence of the control is enough to keep some potential attackers from attempting to circumvent the control. This is often because the effort required to circumvent the control is far greater than the potential reward if the attacker is successful, or, conversely, the negative implications of a failed attack (or getting caught) outweigh the benefits of success. For example, by forcing the identification and authentication of a user, service, or application, and all that it implies, the potential for incidents associated with the system is significantly reduced because an attacker will fear association with the incident. If there are no controls for a given access path, the number of incidents and the potential impact become infinite. Controls inherently reduce exposure to risk by applying oversight for a process. This oversight acts as a deterrent, curbing an attacker's appetite in the face of probable repercussions. The best example of a deterrent control is demonstrated by employees and their propensity to intentionally perform unauthorized functions, leading to unwanted events. When users begin to understand that by authenticating into a system to perform a function, their activities are logged and monitored, and it reduces the likelihood they will attempt such an action. Many threats are based on the anonymity of the threat agent, and any potential for identification and association with their actions is avoided at all costs. It is this fundamental reason why access controls are the key target of circumvention by attackers. Deterrents also take the form of potential punishment if users do something unauthorized. For example, if the organization policy specifies that an employee installing an unauthorized wireless access point will be fired, that will determine most employees from installing wireless access points.

Preventative Controls

Preventive controls are intended to avoid an incident from occurring. Preventative access controls keep a user from performing some activity or function. Preventative controls differ from deterrent controls in that the control

is not optional and cannot (easily) be bypassed. Deterrent controls work on the theory that it is easier to obey the control rather than to risk the consequences of bypassing the control. In other words, the power for action resides with the user (or the attacker). Preventative controls place the power of action with the system, obeying the control is not optional. The only way to bypass the control is to find a flaw in the control's implementation.

Compensating Controls

Compensating controls are introduced when the existing capabilities of a system do not support the requirement of a policy. Compensating controls can be technical, procedural, or managerial. Although an existing system may not support the required controls, there may exist other technology or processes that can supplement the existing environment, closing the gap in controls, meeting policy requirements, and reducing overall risk. For example, the access control policy may state that the authentication process must be encrypted when performed over the Internet. Adjusting an application to natively support encryption for authentication purposes may be too costly. Secure Socket Layer (SSL), an encryption protocol, can be employed and layered on top of the authentication process to support the policy statement. Other examples include a separation of duties environment, which offers the capability to isolate certain tasks to compensate for technical limitations in the system and ensure the security of transactions. In addition, management processes, such as authorization, supervision, and administration, can be used to compensate for gaps in the access control environment.

Detective Controls

Detective controls warn when something has happened, and are the earliest point in the post-incident timeline. Access controls are a deterrent to threats and can be aggressively utilized to prevent harmful incidents through the application of least privilege. However, the detective nature of access controls can provide significant visibility into the access environment and help organizations manage their access strategy and related security risk. As mentioned previously, strongly managed access privileges provided to an authenticated user offer the ability to reduce the risk exposure of the enterprise's assets by limiting the capabilities that authenticated user has. However, there are few options to control what a user can perform once privileges are provided. For example, if a user is provided write access to a file and that file is damaged, altered, or otherwise negatively impacted (either deliberately or unintentionally), the use of applied access controls will offer visibility into the transaction. The control environment can be established to log activity regarding the identification, authentication, authorization, and use of privileges on a system. This can be used to detect the occurrence of errors, the attempts to perform an unauthorized action, or to validate when provided credentials were exercised. The logging system as a detective device provides evidence of actions (both successful and unsuccessful) and tasks that were executed by authorized users.

Corrective Controls

When a security incident occurs, elements within the security infrastructure may require corrective actions. Corrective controls are actions that seek to alter the security posture of an environment to correct any deficiencies and return the environment to a secure state. A security incident signals the failure of one or more directive, deterrent, preventative, or compensating controls. The detective controls may have triggered an alarm or notification, but now the corrective controls must work to stop the incident in its tracks. Corrective controls can take many forms, all depending on the particular situation at hand or the particular security failure that needs to be dealt with.

Recovery Controls

Any changes to the access control environment, whether in the face of a security incident or to offer temporary compensating controls, need to be accurately reinstated and returned to normal operations. There are several situations that may affect access controls, their applicability, status, or management. Events can include system outages, attacks, project changes, technical demands, administrative gaps, and full-blown disaster situations. For example, if an application is not correctly installed or deployed, it may adversely affect controls placed on system files or even have default administrative accounts unknowingly implemented upon install. Additionally, an employee may be transferred, quit, or be on temporary leave that may affect policy requirements regarding separation of duties. An attack on systems may have resulted in the implantation of a Trojan horse program, potentially exposing private user information, such as credit card information and financial data. In all of these cases, an undesirable situation must be rectified as quickly as possible and controls returned to normal operations.

For your exam you should know below information about different security controls

Deterrent Controls

Deterrent Controls are intended to discourage a potential attacker. Access controls act as a deterrent to threats and attacks by the simple fact that the existence of the control is enough to keep some potential attackers from attempting to circumvent the control. This is often because the effort required to circumvent the control is far greater than the potential reward if the attacker is successful, or, conversely, the negative implications of a failed attack (or getting caught) outweigh the benefits of success. For example, by forcing the identification and authentication of a user, service, or application, and all that it implies, the potential for incidents associated with the system is significantly reduced because an attacker will fear association with the incident. If there are no controls for a given access path, the number of incidents and the potential impact become infinite. Controls inherently reduce exposure to risk by applying oversight for a process. This oversight acts as a deterrent, curbing an attacker's appetite in the face of probable repercussions.

The best example of a deterrent control is demonstrated by employees and their propensity to intentionally perform unauthorized functions, leading to unwanted events.

When users begin to understand that by authenticating into a system to perform a function, their activities are logged and monitored, and it reduces the likelihood they will attempt such an action. Many threats are based on the anonymity of the threat agent, and any potential for identification and association with their actions is avoided at all costs.

It is this fundamental reason why access controls are the key target of circumvention by attackers. Deterrents also take the form of potential punishment if users do something unauthorized. For example, if the organization policy specifies that an employee installing an unauthorized wireless access point will be fired, that will determine most employees from installing wireless access points.

Preventative Controls

Preventive controls are intended to avoid an incident from occurring. Preventative access controls keep a user from performing some activity or function. Preventative controls differ from deterrent controls in that the control is not optional and cannot (easily) be bypassed. Deterrent controls work on the theory that it is easier to obey the control rather than to risk the consequences of bypassing the control. In other words, the power for action resides with the user (or the attacker). Preventative controls place the power of action with the system, obeying the control is not optional. The only way to bypass the control is to find a flaw in the control's implementation.

Compensating Controls

Compensating controls are introduced when the existing capabilities of a system do not support the requirement of a policy. Compensating controls can be technical, procedural, or managerial. Although an existing system may not support the required controls, there may exist other technology or processes that can supplement the existing environment, closing the gap in controls, meeting policy requirements, and reducing overall risk.

For example, the access control policy may state that the authentication process must be encrypted when performed over the Internet. Adjusting an application to natively support encryption for authentication purposes may be too costly. Secure Socket Layer (SSL), an encryption protocol, can be employed and layered on top of the authentication process to support the policy statement.

Other examples include a separation of duties environment, which offers the capability to isolate certain tasks to compensate for technical limitations in the system and ensure the security of transactions. In addition, management processes, such as authorization, supervision, and administration, can be used to compensate for gaps in the access control environment.

Detective Controls

Detective controls warn when something has happened, and are the earliest point in the post-incident timeline. Access controls are a deterrent to threats and can be aggressively utilized to prevent harmful incidents through the application of least privilege. However, the detective nature of access controls can provide significant visibility into the access environment and help organizations manage their access strategy and related security

risk.

As mentioned previously, strongly managed access privileges provided to an authenticated user offer the ability to reduce the risk exposure of the enterprise's assets by limiting the capabilities that authenticated user has. However, there are few options to control what a user can perform once privileges are provided. For example, if a user is provided write access to a file and that file is damaged, altered, or otherwise negatively impacted (either deliberately or unintentionally), the use of applied access controls will offer visibility into the transaction. The control environment can be established to log activity regarding the identification, authentication, authorization, and use of privileges on a system.

This can be used to detect the occurrence of errors, the attempts to perform an unauthorized action, or to validate when provided credentials were exercised. The logging system as a detective device provides evidence of actions (both successful and unsuccessful) and tasks that were executed by authorized users.

Corrective Controls

When a security incident occurs, elements within the security infrastructure may require corrective actions. Corrective controls are actions that seek to alter the security posture of an environment to correct any deficiencies and return the environment to a secure state. A security incident signals the failure of one or more directive, deterrent, preventative, or compensating controls. The detective controls may have triggered an alarm or notification, but now the corrective controls must work to stop the incident in its tracks. Corrective controls can take many forms, all depending on the particular situation at hand or the particular security failure that needs to be dealt with.

Recovery Controls

Any changes to the access control environment, whether in the face of a security incident or to offer temporary compensating controls, need to be accurately reinstated and returned to normal operations. There are several situations that may affect access controls, their applicability, status, or management.

Events can include system outages, attacks, project changes, technical demands, administrative gaps, and full-blown disaster situations. For example, if an application is not correctly installed or deployed, it may adversely affect controls placed on system files or even have default administrative accounts unknowingly implemented upon install.

Additionally, an employee may be transferred, quit, or be on temporary leave that may affect policy requirements regarding separation of duties. An attack on systems may have resulted in the implantation of a Trojan horse program, potentially exposing private user information, such as credit card information and financial data. In all of these cases, an undesirable situation must be rectified as quickly as possible and controls returned to normal operations.

The following answers are incorrect:

The other examples belong to Preventive control.

CISA Review Manual 2014 Page number 44

and

Official ISC2 CISSP guide 3rd edition Page number 50 and 51

QUESTION 13

Which of the following is NOT an example of corrective control?

- A. OS Upgrade
- B. Backup and restore
- C. Contingency planning
- D. System Monitoring

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

The word NOT is used as a keyword in the question. You need to find out a security control from given options which is not corrective control. System Monitoring is a detective control and not a corrective control.

For your exam you should know below information about different security controls

Deterrent Controls

Deterrent Controls are intended to discourage a potential attacker. Access controls act as a deterrent to threats and attacks by the simple fact that the existence of the control is enough to keep some potential attackers from attempting to circumvent the control. This is often because the effort required to circumvent the control is far greater than the potential reward if the attacker is successful, or, conversely, the negative implications of a failed attack (or getting caught) outweigh the benefits of success. For example, by forcing the identification and authentication of a user, service, or application, and all that it implies, the potential for incidents associated with the system is significantly reduced because an attacker will fear association with the incident. If there are no controls for a given access path, the number of incidents and the potential impact become infinite. Controls inherently reduce exposure to risk by applying oversight for a process. This oversight acts as a deterrent, curbing an attacker's appetite in the face of probable repercussions. The best example of a deterrent control is demonstrated by employees and their propensity to intentionally perform unauthorized functions, leading to unwanted events. When users begin to understand that by authenticating into a system to perform a function, their activities are logged and monitored, and it reduces the likelihood they will attempt such an action. Many threats are based on the anonymity of the threat agent, and any potential for identification and association with their actions is avoided at all costs. It is this fundamental reason why access controls are the key target of circumvention by attackers. Deterrents also take the form of potential punishment if users do something unauthorized. For example, if the organization policy specifies that an employee installing an unauthorized wireless access point will be fired, that will determine most employees from installing wireless access points.

Preventative Controls

Preventive controls are intended to avoid an incident from occurring. Preventative access controls keep a user from performing some activity or function.

Preventative controls differ from deterrent controls in that the control is not optional and cannot (easily) be bypassed. Deterrent controls work on the theory that it is easier to obey the control

rather than to risk the consequences of bypassing the control. In other words, the power for action resides with the user (or the attacker). Preventative controls place the power of action with the system, obeying the control is not optional. The only way to bypass the control is to find a flaw in the control's implementation.

Compensating Controls

Compensating controls are introduced when the existing capabilities of a system do not support the requirement of a policy. Compensating controls can be technical, procedural, or managerial. Although an existing system may not support the required controls, there may exist other technology or processes that can supplement the existing environment, closing the gap in controls, meeting policy requirements, and reducing overall risk. For example, the access control policy may state that the authentication process must be encrypted when performed over the Internet. Adjusting an application to natively support encryption for authentication purposes may be too costly. Secure Socket Layer (SSL), an encryption protocol, can be employed and layered on top of the authentication process to support the policy statement. Other examples include a separation of duties environment, which offers the capability to isolate certain tasks to compensate for technical limitations in the system and ensure the security of transactions. In addition, management processes, such as authorization, supervision, and administration, can be used to compensate for gaps in the access control environment.

Detective Controls

Detective controls warn when something has happened, and are the earliest point in the post-incident timeline. Access controls are a deterrent to threats and can be aggressively utilized to prevent harmful incidents through the application of least privilege. However, the detective

nature of access controls can provide significant visibility into the access environment and help organizations manage their access strategy and related security risk. As mentioned previously, strongly managed access privileges provided to an authenticated user offer the ability to reduce the risk exposure of the enterprise's assets by limiting the capabilities that authenticated user has. However, there are few options to control what a user can perform once privileges are provided. For example, if a user is provided write access to a file and that file is damaged, altered, or otherwise negatively impacted (either deliberately or unintentionally), the use of applied access controls will offer visibility into the transaction. The control environment can be established to log activity regarding the identification, authentication, authorization, and use of privileges on a system. This can be used to detect the occurrence of errors, the attempts to perform an unauthorized action, or to validate when provided credentials were exercised. The logging system as a detective device provides evidence of actions (both successful and unsuccessful) and tasks that were executed by authorized users.

Corrective Controls

When a security incident occurs, elements within the security infrastructure may require corrective actions. Corrective controls are actions that seek to alter the security posture of an environment to correct any deficiencies and return the environment to a secure state. A security incident signals the failure of one or more directive, deterrent, preventative, or compensating controls. The detective controls may have triggered an alarm or notification, but now the corrective controls must work to stop the incident in its tracks. Corrective controls can take

many forms, all depending on the particular situation at hand or the particular security failure that needs to be dealt with.

Recovery Controls

Any changes to the access control environment, whether in the face of a security incident or to offer temporary compensating controls, need to be accurately reinstated and returned to normal operations. There are several situations that may affect access controls, their applicability, status, or management. Events can include system outages, attacks, project changes, technical demands, administrative gaps, and full-blown disaster situations. For example, if an application is not correctly installed or deployed, it may adversely affect controls placed on system files or even have default administrative accounts unknowingly implemented upon install. Additionally, an employee may be transferred, quit, or be on temporary leave that may affect policy requirements regarding separation of duties. An attack on systems may have resulted in the implantation of a Trojan horse program, potentially exposing private user information, such as credit card information and financial data. In all of these cases, an undesirable situation must be rectified as quickly as possible and controls returned to normal operations.

For your exam you should know below information about different security controls

Deterrent Controls

Deterrent Controls are intended to discourage a potential attacker. Access controls act as a deterrent to threats and attacks by the simple fact that the existence of the control is enough to keep some potential attackers from attempting to circumvent the control. This is often because the effort required to circumvent the control is far greater than the potential reward if the attacker is successful, or, conversely, the negative implications of a failed attack (or getting caught) outweigh the benefits of success. For example, by forcing the identification and authentication of a user, service, or application, and all that it implies, the potential for incidents associated with the system is significantly reduced because an attacker will fear association with the incident. If there are no controls for a given access path, the number of incidents and the potential impact become infinite. Controls inherently reduce exposure to risk by applying oversight for a process. This oversight acts as a deterrent, curbing an attacker's appetite in the face of probable repercussions.

The best example of a deterrent control is demonstrated by employees and their propensity to intentionally perform unauthorized functions, leading to unwanted events.

When users begin to understand that by authenticating into a system to perform a function, their activities are logged and monitored, and it reduces the likelihood they will attempt such an action. Many threats are based on the anonymity of the threat agent, and any potential for identification and association with their actions is avoided at all costs.

It is this fundamental reason why access controls are the key target of circumvention by attackers. Deterrents also take the form of potential punishment if users do something unauthorized. For example, if the organization

policy specifies that an employee installing an unauthorized wireless access point will be fired, that will determine most employees from installing wireless access points.

Preventative Controls

Preventative controls are intended to avoid an incident from occurring. Preventative access controls keep a user from performing some activity or function.

Preventative controls differ from deterrent controls in that the control is not optional and cannot (easily) be bypassed. Deterrent controls work on the theory that it is easier to obey the control rather than to risk the consequences of bypassing the control. In other words, the power for action resides with the user (or the attacker). Preventative controls place the power of action with the system, obeying the control is not optional. The only way to bypass the control is to find a flaw in the control's implementation.

Compensating Controls

Compensating controls are introduced when the existing capabilities of a system do not support the requirement of a policy. Compensating controls can be technical, procedural, or managerial. Although an existing system may not support the required controls, there may exist other technology or processes that can supplement the existing environment, closing the gap in controls, meeting policy requirements, and reducing overall risk.

For example, the access control policy may state that the authentication process must be encrypted when performed over the Internet. Adjusting an application to natively support encryption for authentication purposes may be too costly. Secure Socket Layer (SSL), an encryption protocol, can be employed and layered on top of the authentication process to support the policy statement.

Other examples include a separation of duties environment, which offers the capability to isolate certain tasks to compensate for technical limitations in the system and ensure the security of transactions. In addition, management processes, such as authorization, supervision, and administration, can be used to compensate for gaps in the access control environment.

Detective Controls

Detective controls warn when something has happened, and are the earliest point in the post-incident timeline. Access controls are a deterrent to threats and can be aggressively utilized to prevent harmful incidents through the application of least privilege. However, the detective nature of access controls can provide significant visibility into the access environment and help organizations manage their access strategy and related security risk.

As mentioned previously, strongly managed access privileges provided to an authenticated user offer the ability to reduce the risk exposure of the enterprise's assets by limiting the capabilities that authenticated user has. However, there are few options to control what a user can perform once privileges are provided. For example, if a user is provided write access to a file and that file is damaged, altered, or otherwise negatively impacted (either deliberately or unintentionally), the use of applied access controls will offer visibility into the transaction. The control environment can be established to log activity regarding the identification, authentication, authorization, and use of privileges on a system.

This can be used to detect the occurrence of errors, the attempts to perform an unauthorized action, or to validate when provided credentials were exercised. The logging system as a detective device provides evidence of actions (both successful and unsuccessful) and tasks that were executed by authorized users.

Corrective Controls

When a security incident occurs, elements within the security infrastructure may require corrective actions. Corrective controls are actions that seek to alter the security posture of an environment to correct any deficiencies and return the environment to a secure state. A security incident signals the failure of one or more directive, deterrent, preventative, or compensating controls. The detective controls may have triggered an alarm or notification, but now the corrective controls must work to stop the incident in its tracks. Corrective controls can take many forms, all depending on the particular situation at hand or the particular security failure that needs to be dealt with.

Recovery Controls

Any changes to the access control environment, whether in the face of a security incident or to offer temporary

compensating controls, need to be accurately reinstated and returned to normal operations. There are several situations that may affect access controls, their applicability, status, or management.

Events can include system outages, attacks, project changes, technical demands, administrative gaps, and full-blown disaster situations. For example, if an application is not correctly installed or deployed, it may adversely affect controls placed on system files or even have default administrative accounts unknowingly implemented upon install.

Additionally, an employee may be transferred, quit, or be on temporary leave that may affect policy requirements regarding separation of duties. An attack on systems may have resulted in the implantation of a Trojan horse program, potentially exposing private user information, such as credit card information and financial data. In all of these cases, an undesirable situation must be rectified as quickly as possible and controls returned to normal operations.

The following answers are incorrect:

The other examples belong to corrective control.

CISA Review Manual 2014 Page number 44

and

Official ISC2 CISSP guide 3rd edition Page number 50 and 51

QUESTION 14

Which of the following audit include specific tests of control to demonstrate adherence to specific regulatory or industry standard?

- A. Compliance Audit
- B. Financial Audit
- C. Operational Audit
- D. Forensic audit

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines. Independent accounting, security or IT consultants evaluate the strength and thoroughness of compliance preparations. Auditors review security policies, user access controls and risk management procedures over the course of a compliance audit. Compliance audit include specific tests of controls to demonstrate adherence to specific regulatory or industry standard. These audits often overlap traditional audits, but may focus on particular system or data.

For your exam you should know below information about different types of audit:

What is an audit?

An audit in general terms is a process of evaluating an individual or organization's accounts. This is usually done by an independent auditing body. Thus, audit involves a competent and independent person obtaining evidence and evaluating it objectively with regard to a given entity, which in this case is the subject of audit, in order to establish conformance to a given set of standards. Audit can be on a person, organization, system, enterprise, project or product.

Compliance Audit

A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines.

Independent accounting, security or IT consultants evaluate the strength and thoroughness of compliance preparations. Auditors review security policies, user access controls and risk management procedures over the course of a compliance audit. Compliance audit include specific tests of controls to demonstrate adherence to specific regulatory or industry standard. These audits often overlap traditional audits, but may focus on particular system or data.

What, precisely, is examined in a compliance audit will vary depending upon whether an organization is a public or private company, what kind of data it handles and if it transmits or stores sensitive financial data. For instance, SOX requirements mean that any electronic communication must be backed up and secured with reasonable disaster recovery infrastructure. Health care providers that store or transmit e-health records, like personal health information, are subject to HIPAA requirements. Financial services companies that transmit credit card data are subject to PCI DSS requirements. In each case, the organization must be able to demonstrate compliance by producing an audit trail, often generated by data from event log management software.

Financial Audit

A financial audit, or more accurately, an audit of financial statements, is the verification of the financial statements of a legal entity, with a view to express an audit opinion. The audit opinion is intended to provide reasonable assurance, but not absolute assurance, that the financial statements are presented fairly, in all material respects, and/or give a true and fair view in accordance with the financial reporting framework. The purpose of an audit is to provide an objective independent examination of the financial statements, which increases the value and credibility of the financial statements produced by management, thus increase user confidence in the financial statement, reduce investor risk and consequently reduce the cost of capital of the preparer of the financial statements.

Operational Audit

Operational Audit is a systematic review of effectiveness, efficiency and economy of operation. Operational audit is a future-oriented, systematic, and independent evaluation of organizational activities. In Operational audit financial data may be used, but the primary sources of evidence are the operational policies and achievements related to organizational objectives. Operational audit is a more comprehensive form of an Internal audit.

The Institute of Internal Auditor (IIA) defines Operational Audit as a systematic process of evaluating an organization's effectiveness, efficiency and economy of operations under management's control and reporting to appropriate persons the results of the evaluation along with recommendations for improvement.

Objectives

To appraise the effectiveness and efficiency of a division, activity, or operation of the entity in meeting organizational goals.

To understand the responsibilities and risks faced by an organization. To identify, with management participation, opportunities for improving control. To provide senior management of the organization with a detailed understanding of the Operations.

Integrated Audits

An integrated audit combines financial and operational audit steps. An integrated audit is also performed to assess overall objectives within an organization, related to financial information and asset, safeguarding, efficiency and or internal auditors and would include compliance test of internal controls and substantive audit step.

IS Audit

An information technology audit, or information systems audit, is an examination of the management controls within an Information technology (IT) infrastructure. The evaluation of obtained evidence determines if the information systems are safeguarding assets, maintaining data integrity, and operating effectively to achieve the organization's goals or objectives. These reviews may be performed in conjunction with a financial statement audit, internal audit, or other form of attestation engagement.

The primary functions of an IT audit are to evaluate the systems that are in place to guard an organization's information. Specifically, information technology audits are used to evaluate the organization's ability to protect its information assets and to properly dispense information to authorized parties. The IT audit aims to evaluate

the following:

Will the organization's computer systems be available for the business at all times when required? (known as availability) Will the information in the systems be disclosed only to authorized users? (known as security and confidentiality) Will the information provided by the system always be accurate, reliable, and timely? (measures the integrity) In this way, the audit hopes to assess the risk to the company's valuable asset (its information) and establish methods of minimizing those risks.

Forensic Audit

Forensic audit is the activity that consists of gathering, verifying, processing, analyzing of and reporting on data in order to obtain facts and/or evidence - in a predefined context - in the area of legal/financial disputes and or irregularities (including fraud) and giving preventative advice.

The purpose of a forensic audit is to use accounting procedures to collect evidence for the prosecution or investigation of financial crimes such as theft or fraud. Forensic audits may be conducted to determine if wrongdoing occurred, or to gather materials for the case against an alleged criminal.

The following answers are incorrect:

Financial Audit- A financial audit, or more accurately, an audit of financial statements, is the verification of the financial statements of a legal entity, with a view to express an audit opinion. The audit opinion is intended to provide reasonable assurance, but not absolute assurance, that the financial statements are presented fairly, in all material respects, and/or give a true and fair view in accordance with the financial reporting framework.

Operational Audit - Operational Audit is a systematic review of effectiveness, efficiency and economy of operation. Operational audit is a future-oriented, systematic, and independent evaluation of organizational activities. In Operational audit financial data may be used, but the primary sources of evidence are the operational policies and achievements related to organizational objectives. [1] Operational audit is a more comprehensive form of an Internal audit.

Forensic Audit - Forensic audit is the activity that consists of gathering, verifying, processing, analyzing of and reporting on data in order to obtain facts and/or evidence - in a predefined context - in the area of legal/ financial disputes and or irregularities (including fraud) and giving preventative advice.

CISA Review Manual 2014 Page number 47

<http://search.proquest.com/definition/compliance-audit> http://en.wikipedia.org/wiki/Financial_audit

http://en.wikipedia.org/wiki/Operational_auditing

http://en.wikipedia.org/wiki/Information_technology_audit

http://www.investorwords.com/16445/forensic_audit.html

QUESTION 15

Which of the following audit assess accuracy of financial reporting?

- A. Compliance Audit
- B. Financial Audit
- C. Operational Audit
- D. Forensic audit

Correct Answer: B
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

A financial audit, or more accurately, an audit of financial statements, is the verification of the financial statements of a legal entity, with a view to express an audit opinion. The audit opinion is intended to provide reasonable assurance, but not absolute assurance, that the financial statements are presented fairly, in all material respects, and/or give a true and fair view in accordance with the financial reporting framework. The purpose of an audit is to provide an objective independent examination of the financial statements, which increases the value and credibility of the financial statements produced by management, thus increase user confidence in the financial statement, reduce investor risk and consequently reduce the cost of capital of the preparer of the financial statements.

For your exam you should know below information about different types of audit:

What is an audit?

An audit in general terms is a process of evaluating an individual or organization's accounts. This is usually done by an independent auditing body. Thus, audit involves a competent and independent person obtaining evidence and evaluating it objectively with regard to a given entity, which in this case is the subject of audit, in order to establish conformance to a given set of standards. Audit can be on a person, organization, system, enterprise, project or product.

Compliance Audit

A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines. Independent accounting, security or IT consultants evaluate the strength and thoroughness of compliance preparations. Auditors review security policies, user access controls and risk management procedures over the course of a compliance audit. Compliance audit include specific tests of controls to demonstrate adherence to specific regulatory or industry standard. These audits often overlap traditional audits, but may focus on particular system or data.

What, precisely, is examined in a compliance audit will vary depending upon whether an organization is a public or private company, what kind of data it handles and if it transmits or stores sensitive financial data. For instance, SOX requirements mean that any electronic communication must be backed up and secured with reasonable disaster recovery infrastructure. Health care providers that store or transmit e-health records, like personal health information, are subject to HIPAA requirements. Financial services companies that transmit credit card data are subject to PCI DSS requirements. In each case, the organization must be able to demonstrate compliance by producing an audit trail, often generated by data from event log management software.

Financial Audit

A financial audit, or more accurately, an audit of financial statements, is the verification of the financial statements of a legal entity, with a view to express an audit opinion. The audit opinion is intended to provide reasonable assurance, but not absolute assurance, that the financial statements are presented fairly, in all material respects, and/or give a true and fair view in accordance with the financial reporting framework. The purpose of an audit is to provide an objective independent examination of the financial statements, which increases the value and credibility of the financial statements produced by management, thus increase user confidence in the financial statement, reduce investor risk and consequently reduce the cost of capital of the preparer of the financial statements.

Operational Audit

Operational Audit is a systematic review of effectiveness, efficiency and economy of operation. Operational audit is a future-oriented, systematic, and independent evaluation of organizational activities. In Operational audit financial data may be used, but the primary sources of evidence are the operational policies and achievements related to organizational objectives. Operational audit is a more comprehensive form of an Internal audit.

The Institute of Internal Auditor (IIA) defines Operational Audit as a systematic process of evaluating an organization's effectiveness, efficiency and economy of operations under management's control and reporting to appropriate persons the results of the evaluation along with recommendations for improvement.

Objectives

To appraise the effectiveness and efficiency of a division, activity, or operation of the entity in meeting organizational goals.

To understand the responsibilities and risks faced by an organization. To identify, with management participation, opportunities for improving control. To provide senior management of the organization with a detailed understanding of the Operations.

Integrated Audits

An integrated audit combines financial and operational audit steps. An integrated audit is also performed to assess overall objectives within an organization, related to financial information and asset, safeguarding, efficiency and or internal auditors and would include compliance test of internal controls and substantive audit step.

IS Audit

An information technology audit, or information systems audit, is an examination of the management controls within an Information technology (IT) infrastructure. The evaluation of obtained evidence determines if the information systems are safeguarding assets, maintaining data integrity, and operating effectively to achieve the organization's goals or objectives. These reviews may be performed in conjunction with a financial statement audit, internal audit, or other form of attestation engagement.

The primary functions of an IT audit are to evaluate the systems that are in place to guard an organization's information. Specifically, information technology audits are used to evaluate the organization's ability to protect its information assets and to properly dispense information to authorized parties. The IT audit aims to evaluate the following:

Will the organization's computer systems be available for the business at all times when required? (known as availability) Will the information in the systems be disclosed only to authorized users? (known as security and confidentiality) Will the information provided by the system always be accurate, reliable, and timely? (measures the integrity) In this way, the audit hopes to assess the risk to the company's valuable asset (its information) and establish methods of minimizing those risks.

Forensic Audit

Forensic audit is the activity that consists of gathering, verifying, processing, analyzing of and reporting on data in order to obtain facts and/or evidence - in a predefined context - in the area of legal/financial disputes and or irregularities (including fraud) and giving preventative advice.

The purpose of a forensic audit is to use accounting procedures to collect evidence for the prosecution or investigation of financial crimes such as theft or fraud. Forensic audits may be conducted to determine if wrongdoing occurred, or to gather materials for the case against an alleged criminal.

The following answers are incorrect:

Compliance Audit - A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines. Independent accounting, security or IT consultants evaluate the strength and thoroughness of compliance preparations. Auditors review security policies, user access controls and risk management procedures over the course of a compliance audit. Compliance audit include specific tests of controls to demonstrate adherence to specific regulatory or industry standard. These audits often overlap traditional audits, but may focus on particular system or data.

Operational Audit - Operational Audit is a systematic review of effectiveness, efficiency and economy of operation. Operational audit is a future-oriented, systematic, and independent evaluation of organizational activities. In Operational audit financial data may be used, but the primary sources of evidence are the operational policies and achievements related to organizational objectives.[1] Operational audit is a more comprehensive form of an Internal audit.

Forensic Audit - Forensic audit is the activity that consists of gathering, verifying, processing, analyzing of and reporting on data in order to obtain facts and/or evidence - in a predefined context - in the area of legal/ financial disputes and or irregularities (including fraud) and giving preventative advice.

CISA Review Manual 2014 Page number 44

<http://searchcompliance.techtarget.com/definition/compliance-audit> http://en.wikipedia.org/wiki/Financial_audit

http://en.wikipedia.org/wiki/Operational_auditing

http://en.wikipedia.org/wiki/Information_technology_audit

http://www.investorwords.com/16445/forensic_audit.html

QUESTION 16

Which of the following audit is mainly designed to evaluate the internal control structure in a given process or area?

- A. Compliance Audit
- B. Financial Audit
- C. Operational Audit
- D. Forensic audit

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Operational audit is mainly designed to evaluate the internal control structure in a given process or area. Operational Audit is a systematic review of effectiveness, efficiency and economy of operation. Operational audit is a future-oriented, systematic, and independent evaluation of organizational activities. In Operational audit financial data may be used, but the primary sources of evidence are the operational policies and achievements related to organizational objectives. Operational audit is a more comprehensive form of an Internal audit.

For your exam you should know below information about different types of audit:

What is an audit?

An audit in general terms is a process of evaluating an individual or organization's accounts. This is usually done by an independent auditing body. Thus, audit involves a competent and independent person obtaining evidence and evaluating it objectively with regard to a given entity, which in this case is the subject of audit, in order to establish conformance to a given set of standards. Audit can be on a person, organization, system, enterprise, project or product.

Compliance Audit

A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines. Independent accounting, security or IT consultants evaluate the strength and thoroughness of compliance preparations. Auditors review security policies, user access controls and risk management procedures over the course of a compliance audit. Compliance audit include specific tests of controls to demonstrate adherence to specific regulatory or industry standard. These audits often overlap traditional audits, but may focus on particular system or data.

What, precisely, is examined in a compliance audit will vary depending upon whether an organization is a public or private company, what kind of data it handles and if it transmits or stores sensitive financial data. For instance, SOX requirements mean that any electronic communication must be backed up and secured with reasonable disaster recovery infrastructure. Health care providers that store or transmit e-health records, like personal health information, are subject to HIPAA requirements. Financial services companies that transmit credit card data are subject to PCI DSS requirements. In each case, the organization must be able to demonstrate compliance by producing an audit trail, often generated by data from event log management software.

Financial Audit

A financial audit, or more accurately, an audit of financial statements, is the verification of the financial statements of a legal entity, with a view to express an audit opinion. The audit opinion is intended to provide reasonable assurance, but not absolute assurance, that the financial statements are presented fairly, in all material respects, and/or give a true and fair view in accordance with the financial reporting framework. The purpose of an audit is to provide an objective independent examination of the financial statements, which increases the value and credibility of the financial statements produced by management, thus increase user confidence in the financial statement, reduce investor risk and consequently reduce the cost of capital of the preparer of the financial statements.

Operational Audit

Operational Audit is a systematic review of effectiveness, efficiency and economy of operation. Operational audit is a future-oriented, systematic, and independent evaluation of organizational activities. In Operational audit financial data may be used, but the primary sources of evidence are the operational policies and achievements related to organizational objectives. Operational audit is a more comprehensive form of an Internal audit.

The Institute of Internal Auditor (IIA) defines Operational Audit as a systematic process of evaluating an organization's effectiveness, efficiency and economy of operations under management's control and reporting to appropriate persons the results of the evaluation along with recommendations for improvement.

Objectives

To appraise the effectiveness and efficiency of a division, activity, or operation of the entity in meeting organizational goals.

To understand the responsibilities and risks faced by an organization. To identify, with management participation, opportunities for improving control. To provide senior management of the organization with a detailed understanding of the Operations.

Integrated Audits

An integrated audit combines financial and operational audit steps. An integrated audit is also performed to assess overall objectives within an organization, related to financial information and asset, safeguarding, efficiency and or internal auditors and would include compliance test of internal controls and substantive audit step.

IS Audit

An information technology audit, or information systems audit, is an examination of the management controls within an Information technology (IT) infrastructure. The evaluation of obtained evidence determines if the information systems are safeguarding assets, maintaining data integrity, and operating effectively to achieve the organization's goals or objectives. These reviews may be performed in conjunction with a financial statement audit, internal audit, or other form of attestation engagement.

The primary functions of an IT audit are to evaluate the systems that are in place to guard an organization's information. Specifically, information technology audits are used to evaluate the organization's ability to protect its information assets and to properly dispense information to authorized parties. The IT audit aims to evaluate the following:

Will the organization's computer systems be available for the business at all times when required? (known as availability) Will the information in the systems be disclosed only to authorized users? (known as security and confidentiality) Will the information provided by the system always be accurate, reliable, and timely? (measures the integrity) In this way, the audit hopes to assess the risk to the company's valuable asset (its information) and establish methods of minimizing those risks.

Forensic Audit

Forensic audit is the activity that consists of gathering, verifying, processing, analyzing of and reporting on data in order to obtain facts and/or evidence - in a predefined context - in the area of legal/financial disputes and or irregularities (including fraud) and giving preventative advice.

The purpose of a forensic audit is to use accounting procedures to collect evidence for the prosecution or

investigation of financial crimes such as theft or fraud. Forensic audits may be conducted to determine if wrongdoing occurred, or to gather materials for the case against an alleged criminal.

The following answers are incorrect:

Compliance Audit - A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines. Independent accounting, security or IT consultants evaluate the strength and thoroughness of compliance preparations. Auditors review security policies, user access controls and risk management procedures over the course of a compliance audit. Compliance audit include specific tests of controls to demonstrate adherence to specific regulatory or industry standard. These audits often overlap traditional audits, but may focus on particular system or data.

Financial Audit - A financial audit, or more accurately, an audit of financial statements, is the verification of the financial statements of a legal entity, with a view to express an audit opinion. The audit opinion is intended to provide reasonable assurance, but not absolute assurance, that the financial statements are presented fairly, in all material respects, and/or give a true and fair view in accordance with the financial reporting framework. The purpose of an audit is to provide an objective independent examination of the financial statements, which increases the value and credibility of the financial statements produced by management, thus increase user confidence in the financial statement, reduce investor risk and consequently reduce the cost of capital of the preparer of the financial statements.

Forensic Audit - Forensic audit is the activity that consists of gathering, verifying, processing, analyzing of and reporting on data in order to obtain facts and/or evidence - in a predefined context - in the area of legal/ financial disputes and or irregularities (including fraud) and giving preventative advice.

CISA Review Manual 2014 Page number 44

<http://search.proquest.com/definition/compliance-audit> http://en.wikipedia.org/wiki/Financial_audit

http://en.wikipedia.org/wiki/Operational_auditing

http://en.wikipedia.org/wiki/Information_technology_audit

http://www.investorwords.com/16445/forensic_audit.html

QUESTION 17

Which of the following audit combines financial and operational audit steps?

- A. Compliance Audit
- B. Financial Audit
- C. Integrated Audit
- D. Forensic audit

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

An integrated audit combines financial and operational audit steps. An integrated audit is also performed to assess overall objectives within an organization, related to financial information and asset, safeguarding, efficiency and or internal auditors and would include compliance test of internal controls and substantive audit step.

For your exam you should know below information about different types of audit:

What is an audit?

An audit in general terms is a process of evaluating an individual or organization's accounts. This is usually

done by an independent auditing body. Thus, audit involves a competent and independent person obtaining evidence and evaluating it objectively with regard to a given entity, which in this case is the subject of audit, in order to establish conformance to a given set of standards. Audit can be on a person, organization, system, enterprise, project or product.

Compliance Audit

A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines. Independent accounting, security or IT consultants evaluate the strength and thoroughness of compliance preparations. Auditors review security policies, user access controls and risk management procedures over the course of a compliance audit. Compliance audit include specific tests of controls to demonstrate adherence to specific regulatory or industry standard. These audits often overlap traditional audits, but may focus on particular system or data.

What, precisely, is examined in a compliance audit will vary depending upon whether an organization is a public or private company, what kind of data it handles and if it transmits or stores sensitive financial data. For instance, SOX requirements mean that any electronic communication must be backed up and secured with reasonable disaster recovery infrastructure. Health care providers that store or transmit e-health records, like personal health information, are subject to HIPAA requirements. Financial services companies that transmit credit card data are subject to PCI DSS requirements. In each case, the organization must be able to demonstrate compliance by producing an audit trail, often generated by data from event log management software.

Financial Audit

A financial audit, or more accurately, an audit of financial statements, is the verification of the financial statements of a legal entity, with a view to express an audit opinion. The audit opinion is intended to provide reasonable assurance, but not absolute assurance, that the financial statements are presented fairly, in all material respects, and/or give a true and fair view in accordance with the financial reporting framework. The purpose of an audit is to provide an objective independent examination of the financial statements, which increases the value and credibility of the financial statements produced by management, thus increase user confidence in the financial statement, reduce investor risk and consequently reduce the cost of capital of the preparer of the financial statements.

Operational Audit

Operational Audit is a systematic review of effectiveness, efficiency and economy of operation. Operational audit is a future-oriented, systematic, and independent evaluation of organizational activities. In Operational audit financial data may be used, but the primary sources of evidence are the operational policies and achievements related to organizational objectives. Operational audit is a more comprehensive form of an Internal audit.

The Institute of Internal Auditor (IIA) defines Operational Audit as a systematic process of evaluating an organization's effectiveness, efficiency and economy of operations under management's control and reporting to appropriate persons the results of the evaluation along with recommendations for improvement.

Objectives

To appraise the effectiveness and efficiency of a division, activity, or operation of the entity in meeting organizational goals.

To understand the responsibilities and risks faced by an organization. To identify, with management participation, opportunities for improving control. To provide senior management of the organization with a detailed understanding of the Operations.

Integrated Audits

An integrated audit combines financial and operational audit steps. An integrated audit is also performed to assess overall objectives within an organization, related to financial information and asset, safeguarding, efficiency and or internal auditors and would include compliance test of internal controls and substantive audit step.

IS Audit

An information technology audit, or information systems audit, is an examination of the management controls

within an Information technology (IT) infrastructure. The evaluation of obtained evidence determines if the information systems are safeguarding assets, maintaining data integrity, and operating effectively to achieve the organization's goals or objectives. These reviews may be performed in conjunction with a financial statement audit, internal audit, or other form of attestation engagement.

The primary functions of an IT audit are to evaluate the systems that are in place to guard an organization's information. Specifically, information technology audits are used to evaluate the organization's ability to protect its information assets and to properly dispense information to authorized parties. The IT audit aims to evaluate the following:

Will the organization's computer systems be available for the business at all times when required? (known as availability) Will the information in the systems be disclosed only to authorized users? (known as security and confidentiality) Will the information provided by the system always be accurate, reliable, and timely? (measures the integrity) In this way, the audit hopes to assess the risk to the company's valuable asset (its information) and establish methods of minimizing those risks.

Forensic Audit

Forensic audit is the activity that consists of gathering, verifying, processing, analyzing of and reporting on data in order to obtain facts and/or evidence - in a predefined context - in the area of legal/financial disputes and or irregularities (including fraud) and giving preventative advice.

The purpose of a forensic audit is to use accounting procedures to collect evidence for the prosecution or investigation of financial crimes such as theft or fraud. Forensic audits may be conducted to determine if wrongdoing occurred, or to gather materials for the case against an alleged criminal.

The following answers are incorrect:

Compliance Audit - A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines. Independent accounting, security or IT consultants evaluate the strength and thoroughness of compliance preparations. Auditors review security policies, user access controls and risk management procedures over the course of a compliance audit. Compliance audit include specific tests of controls to demonstrate adherence to specific regulatory or industry standard. These audits often overlap traditional audits, but may focus on particular system or data.

Financial Audit - A financial audit, or more accurately, an audit of financial statements, is the verification of the financial statements of a legal entity, with a view to express an audit opinion. The audit opinion is intended to provide reasonable assurance, but not absolute assurance, that the financial statements are presented fairly, in all material respects, and/or give a true and fair view in accordance with the financial reporting framework. The purpose of an audit is to provide an objective independent examination of the financial statements, which increases the value and credibility of the financial statements produced by management, thus increase user confidence in the financial statement, reduce investor risk and consequently reduce the cost of capital of the preparer of the financial statements.

Forensic Audit - Forensic audit is the activity that consists of gathering, verifying, processing, analyzing of and reporting on data in order to obtain facts and/or evidence - in a predefined context - in the area of legal/ financial disputes and or irregularities (including fraud) and giving preventative advice.

CISA Review Manual 2014 Page number 44

<http://search.proquest.com/definition/compliance-audit> http://en.wikipedia.org/wiki/Financial_audit

http://en.wikipedia.org/wiki/Operational_auditing

http://en.wikipedia.org/wiki/Information_technology_audit

http://www.investorwords.com/16445/forensic_audit.html

QUESTION 18

Which of the following audit mainly focuses on discovering and disclosing on frauds and crimes?

- A. Compliance Audit
- B. Financial Audit
- C. Integrated Audit
- D. Forensic audit

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Forensic audit is the activity that consists of gathering, verifying, processing, analyzing of and reporting on data in order to obtain facts and/or evidence - in a predefined context - in the area of legal/financial disputes and or irregularities (including fraud) and giving preventative advice

For your exam you should know below information about different types of audit:

What is an audit?

An audit in general terms is a process of evaluating an individual or organization's accounts. This is usually done by an independent auditing body. Thus, audit involves a competent and independent person obtaining evidence and evaluating it objectively with regard to a given entity, which in this case is the subject of audit, in order to establish conformance to a given set of standards. Audit can be on a person, organization, system, enterprise, project or product.

Compliance Audit

A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines. Independent accounting, security or IT consultants evaluate the strength and thoroughness of compliance preparations. Auditors review security policies, user access controls and risk management procedures over the course of a compliance audit. Compliance audit include specific tests of controls to demonstrate adherence to specific regulatory or industry standard. These audits often overlap traditional audits, but may focus on particular system or data.

What, precisely, is examined in a compliance audit will vary depending upon whether an organization is a public or private company, what kind of data it handles and if it transmits or stores sensitive financial data. For instance, SOX requirements mean that any electronic communication must be backed up and secured with reasonable disaster recovery infrastructure. Health care providers that store or transmit e-health records, like personal health information, are subject to HIPAA requirements. Financial services companies that transmit credit card data are subject to PCI DSS requirements. In each case, the organization must be able to demonstrate compliance by producing an audit trail, often generated by data from event log management software.

Financial Audit

A financial audit, or more accurately, an audit of financial statements, is the verification of the financial statements of a legal entity, with a view to express an audit opinion. The audit opinion is intended to provide reasonable assurance, but not absolute assurance, that the financial statements are presented fairly, in all material respects, and/or give a true and fair view in accordance with the financial reporting framework. The purpose of an audit is to provide an objective independent examination of the financial statements, which increases the value and credibility of the financial statements produced by management, thus increase user confidence in the financial statement, reduce investor risk and consequently reduce the cost of capital of the preparer of the financial statements.

Operational Audit

Operational Audit is a systematic review of effectiveness, efficiency and economy of operation. Operational audit is a future-oriented, systematic, and independent evaluation of organizational activities. In Operational audit financial data may be used, but the primary sources of evidence are the operational policies and achievements related to organizational objectives. Operational audit is a more comprehensive form of an

Internal audit.

The Institute of Internal Auditor (IIA) defines Operational Audit as a systematic process of evaluating an organization's effectiveness, efficiency and economy of operations under management's control and reporting to appropriate persons the results of the evaluation along with recommendations for improvement.

Objectives

To appraise the effectiveness and efficiency of a division, activity, or operation of the entity in meeting organizational goals.

To understand the responsibilities and risks faced by an organization. To identify, with management participation, opportunities for improving control. To provide

senior management of the organization with a detailed understanding of the Operations.

Integrated Audits

An integrated audit combines financial and operational audit steps. An integrated audit is also performed to assess overall objectives within an organization, related to financial information and asset, safeguarding, efficiency and or internal auditors and would include compliance test of internal controls and substantive audit step.

IS Audit

An information technology audit, or information systems audit, is an examination of the management controls within an Information technology (IT) infrastructure. The evaluation of obtained evidence determines if the information systems are safeguarding assets, maintaining data integrity, and operating effectively to achieve the organization's goals or objectives. These reviews may be performed in conjunction with a financial statement audit, internal audit, or other form of attestation engagement.

The primary functions of an IT audit are to evaluate the systems that are in place to guard an organization's information. Specifically, information technology audits are used to evaluate the organization's ability to protect its information assets and to properly dispense information to authorized parties. The IT audit aims to evaluate the following:

Will the organization's computer systems be available for the business at all times when required? (known as availability) Will the information in the systems be disclosed only to authorized users? (known as security and confidentiality) Will the information provided by the system always be accurate, reliable, and timely? (measures the integrity) In this way, the audit hopes to assess the risk to the company's valuable asset (its information) and establish methods of minimizing those risks.

Forensic Audit

Forensic audit is the activity that consists of gathering, verifying, processing, analyzing of and reporting on data in order to obtain facts and/or evidence - in a predefined context - in the area of legal/financial disputes and or irregularities (including fraud) and giving preventative advice.

The purpose of a forensic audit is to use accounting procedures to collect evidence for the prosecution or investigation of financial crimes such as theft or fraud. Forensic audits may be conducted to determine if wrongdoing occurred, or to gather materials for the case against an alleged criminal.

The following answers are incorrect:

Compliance Audit - A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines. Independent accounting, security or IT consultants evaluate the strength and thoroughness of compliance preparations. Auditors review security policies, user access controls and risk management procedures over the course of a compliance audit. Compliance audit include specific tests of controls to demonstrate adherence to specific regulatory or industry standard. These audits often overlap traditional audits, but may focus on particular system or data.

Financial Audit- A financial audit, or more accurately, an audit of financial statements, is the verification of the financial statements of a legal entity, with a view to express an audit opinion. The audit opinion is intended to

provide reasonable assurance, but not absolute assurance, that the financial statements are presented fairly, in all material respects, and/or give a true and fair view in accordance with the financial reporting framework. The purpose of an audit is to provide an objective independent examination of the financial statements, which increases the value and credibility of the financial statements produced by management, thus increase user confidence in the financial statement, reduce investor risk and consequently reduce the cost of capital of the preparer of the financial statements.

Integrated Audits - An integrated audit combines financial and operational audit steps. An integrated audit is also performed to assess overall objectives within an organization, related to financial information and asset, safeguarding, efficiency and or internal auditors and would include compliance test of internal controls and substantive audit step.

CISA Review Manual 2014 Page number 44

<http://searchcompliance.techtarget.com/definition/compliance-audit> http://en.wikipedia.org/wiki/Financial_audit

http://en.wikipedia.org/wiki/Operational_auditing

http://en.wikipedia.org/wiki/Information_technology_audit

http://www.investorwords.com/16445/forensic_audit.html

QUESTION 19

Which of the following audit risk is related to exposure of a process or entity to be audited without taking into account the control that management has implemented?

- A. Inherent Risk
- B. Control Risk
- C. Detection Risk
- D. Overall Audit Risk

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Inherent Risk is the risk level or exposure of a process or entity to be audited without taking into account the control that management has implemented. Inherent risk exists independent of an audit and can occur because of the nature of the business.

For your exam you should know below information about audit risk:

Audit risk (also referred to as residual risk) refers to the risk that an auditor may issue unqualified report due to the auditor's failure to detect material misstatement either due to error or fraud. This risk is composed of inherent risk (IR), control risk (CR) and detection risk (DR), and can be calculated thus:

$$AR = IR \times CR \times DR$$

Inherent Risk

Auditors must determine risks when working with clients. One type of risk to be aware of is inherent risk. While assessing this level of risk, you ignore whether the client has internal controls in place (such as a secondary review of financial statements) in order to help mitigate the inherent risk. You consider the strength of the internal controls when assessing the client's control risk. Your job when assessing inherent risk is to evaluate how susceptible the financial statement assertions are to material misstatement given the nature of the client's

business. A few key factors can increase inherent risk.

Environment and external factors: Here are some examples of environment and external factors that can lead to high inherent risk:

Rapid change: A business whose inventory becomes obsolete quickly experiences high inherent risk. Expiring patents: Any business in the pharmaceutical industry also has inherently risky environment and external factors. Drug patents eventually expire, which means the company faces competition from other manufacturers marketing the same drug under a generic label.

State of the economy: The general level of economic growth is another external factor affecting all businesses. Availability of financing: Another external factor is interest rates and the associated availability of financing. If your client is having problems meeting its short-term cash payments, available loans with low interest rates may mean the difference between your client staying in business or having to close its doors. Prior-period misstatements: If a company has made mistakes

in prior years that weren't material (meaning they weren't significant enough to have to change), those errors still exist in the financial statements. You have to aggregate prior-period misstatements with current year misstatements to see if you need to ask the client to adjust the account for the total misstatement.

You may think an understatement in one year compensates for an overstatement in another year. In auditing, this assumption isn't true. Say you work a cash register and one night the register comes up \$20 short. The next week, you somehow came up \$20 over my draw count. The \$20 differences are added together to represent the total amount of your mistakes which is \$40 and not zero. Zero would indicate no mistakes at all had occurred.

Susceptibility to theft or fraud: If a certain asset is susceptible to theft or fraud, the account or balance level may be considered inherently risky. For example, if a client has a lot of customers who pay in cash, the balance sheet cash account is going to have risk associated with theft or fraud because of the fact that cash is more easily diverted than customer checks or credit card payments.

Looking at industry statistics relating to inventory theft, you may also decide to consider the inventory account as inherently risky. Small inventory items can further increase the risk of this account valuation being incorrect because those items are easier to conceal (and therefore easier to steal).

Control Risk

Control risk has been defined under International Standards of Auditing (ISAs) as following:

The risk that a misstatement that could occur in an assertion about a class of transaction, account balance or disclosure and that could be material, either individually or when aggregated with other misstatements, will not be prevented, or detected and corrected, on a timely basis by the entity's internal control.

In simple words control risk is the probability that a material misstatement exists in an assertion because that misstatement was not either prevented from entering entity's financial information or it was not detected and corrected by the internal control system of the entity.

It is the responsibility of the management and those charged with governance to implement internal control system and maintain it appropriately which includes managing control risk.

There can be many reasons for control risk to arise and why it cannot be eliminated absolutely. But some of them are as follows:

- Cost-benefit constraints
- Circumvention of controls
- Inappropriate design of controls
- Inappropriate application of controls
- Lack of control environment and accountability
- Novel situations
- Outdated controls
- Inappropriate segregation of duties

Detection Risk

Detection Risk is the risk that the auditors fail to detect a material misstatement in the financial statements. An auditor must apply audit procedures to detect material misstatements in the financial statements whether due to fraud or error. Misapplication or omission of critical audit procedures may result in a material misstatement remaining undetected by the auditor. Some detection risk is always present due to the inherent limitations of the audit such as the use of sampling for the selection of transactions. Detection risk can be reduced by auditors by increasing the number of sampled transactions for detailed testing.

The following answers are incorrect:

Control Risk - The risk that material error exist that would not be prevented or detected on timely basis by the system of internal controls.

Detection risk - The risk that material errors or misstatements that have occurred will not be detected by an IS auditor.

Overall audit risk - The probability that information or financial report may contain material errors and that the auditor may not detect an error that has occurred. An objective in formulating the audit approach is to limit the audit risk in the area under security so the overall audit risk is at sufficiently low level at the completion of the examination.

CISA review manual 2014 page number 50

http://en.wikipedia.org/wiki/Audit_risk

<http://www.dummies.com/how-to/content/how-to-assess-inherent-risk-in-an-audit.html> <http://pakaccountants.com/what-is-control-risk/>

<http://accounting-simplified.com/audit/risk-assessment/audit-risk.html>

QUESTION 20

Which of the following audit risk is related to material error exist that would not be prevented or detected on timely basis by the system of internal controls?

- A. Inherent Risk
- B. Control Risk
- C. Detection Risk
- D. Overall Audit Risk

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

The risk that material error exist that would not be prevented or detected on timely basis by the system of internal controls. For example, the control risk associated with manual review could be high because activities requiring investigation are often easily missed due to the volume of logged information.

For your exam you should know below information about audit risk:

Audit risk (also referred to as residual risk) refers to the risk that an auditor may issue unqualified report due to the auditor's failure to detect material misstatement either due to error or fraud. This risk is composed of inherent risk (IR), control risk (CR) and detection risk (DR), and can be calculated thus:

$$AR = IR \times CR \times DR$$

Inherent Risk

Auditors must determine risks when working with clients. One type of risk to be aware of is inherent risk. While assessing this level of risk, you ignore whether the client has internal controls in place (such as a secondary review of financial statements) in order to help mitigate the inherent risk. You consider the strength of the internal controls when assessing the client's control risk. Your job when assessing inherent risk is to evaluate how susceptible the financial statement assertions are to material misstatement given the nature of the client's business. A few key factors can increase inherent risk.

Environment and external factors: Here are some examples of environment and external factors that can lead to high inherent risk:

Rapid change: A business whose inventory becomes obsolete quickly experiences high inherent risk. **Expiring patents:** Any business in the pharmaceutical industry also has inherently risky environment and external factors. Drug patents eventually expire, which means the company faces competition from other manufacturers marketing the same drug under a generic label.

State of the economy: The general level of economic growth is another external factor affecting all businesses. **Availability of financing:** Another external factor is interest rates and the associated availability of financing. If your client is having problems meeting its short-term cash payments, available loans with low interest rates may mean the difference between your client staying in business or having to close its doors. **Prior-period misstatements:** If a company has made mistakes in prior years that weren't material (meaning they weren't significant enough to have to change), those errors still exist in the financial statements. You have to

aggregate prior-period misstatements with current year misstatements to see if you need to ask the client to adjust the account for the total misstatement. You may think an understatement in one year compensates for an overstatement in another year. In auditing, this assumption isn't true. Say you work a cash register and one night the register comes up \$20 short. The next week, you somehow came up \$20 over my draw count. The \$20 differences are added together to represent the total amount of your mistakes which is \$40 and not zero. Zero would indicate no mistakes at all had occurred.

Susceptibility to theft or fraud: If a certain asset is susceptible to theft or fraud, the account or balance level may be considered inherently risky. For example, if a client has a lot of customers who pay in cash, the balance sheet cash account is going to have risk associated with theft or fraud because of the fact that cash is more easily diverted than customer checks or credit card payments.

Looking at industry statistics relating to inventory theft, you may also decide to consider the inventory account as inherently risky. Small inventory items can further increase the risk of this account valuation being incorrect because those items are easier to conceal (and therefore easier to steal).

Control Risk

Control risk has been defined under International Standards of Auditing (ISAs) as following:

The risk that a misstatement that could occur in an assertion about a class of transaction, account balance or disclosure and that could be material, either individually or when aggregated with other misstatements, will not be prevented, or detected and corrected, on a timely basis by the entity's internal control.

In simple words control risk is the probability that a material misstatement exists in an assertion because that misstatement was not either prevented from entering entity's financial information or it was not detected and corrected by the internal control system of the entity.

It is the responsibility of the management and those charged with governance to implement internal control system and maintain it appropriately which includes managing control risk.

There can be many reasons for control risk to arise and why it cannot be eliminated absolutely. But some of them are as follows:

- Cost-benefit constraints
- Circumvention of controls
- Inappropriate design of controls
- Inappropriate application of controls

- Lack of control environment and accountability
- Novel situations
- Outdated controls
- Inappropriate segregation of duties

Detection Risk

Detection Risk is the risk that the auditors fail to detect a material misstatement in the financial statements. An auditor must apply audit procedures to detect material misstatements in the financial statements whether due to fraud or error. Misapplication or omission of critical audit procedures may result in a material misstatement remaining undetected by the auditor. Some detection risk is always present due to the inherent limitations of the audit such as the use of sampling for the selection of transactions. Detection risk can be reduced by auditors by increasing the number of sampled transactions for detailed testing.

The following answers are incorrect:

Inherent Risk - It is the risk level or exposure of a process or entity to be audited without taking into account the control that management has implemented.

Detection risk - The risk that material errors or misstatements that have occurred will not be detected by an IS auditor.

Overall audit risk - The probability that information or financial report may contain material errors and that the auditor may not detect an error that has occurred. An objective in formulating the audit approach is to limit the audit risk in the area under security so the overall audit risk is at sufficiently low level at the completion of the examination.

CISA review manual 2014 page number 50

http://en.wikipedia.org/wiki/Audit_risk

<http://www.dummies.com/how-to/content/how-to-assess-inherent-risk-in-an-audit.html> <http://pakaccountants.com/what-is-control-risk/>

<http://accounting-simplified.com/audit/risk-assessment/audit-risk.html>

QUESTION 21

Which of the following audit risk is related to material errors or misstatements that have occurred that will not be detected by an IS auditor?

- A. Inherent Risk
- B. Control Risk
- C. Detection Risk
- D. Overall Audit Risk

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

The risk that material errors or misstatements that have occurred will not be detected by an IS auditor. Detection Risk is the risk that the auditors fail to detect a material misstatement in the financial statements. An auditor must apply audit procedures to detect material misstatements in the financial statements whether due to fraud or error. Misapplication or omission of critical audit procedures may result in a material misstatement remaining undetected by the auditor. Some detection risk is always present due to the inherent limitations of the audit such as the use of sampling for the selection of transactions. Detection risk can be reduced by

auditors by increasing the number of sampled transactions for detailed testing.

For your exam you should know below information about audit risk:

Audit risk (also referred to as residual risk) refers to the risk that an auditor may issue unqualified report due to the auditor's failure to detect material misstatement either due to error or fraud. This risk is composed of inherent risk (IR), control risk (CR) and detection risk (DR), and can be calculated thus:

$$AR = IR \times CR \times DR$$

Inherent Risk

Auditors must determine risks when working with clients. One type of risk to be aware of is inherent risk. While assessing this level of risk, you ignore whether the client has internal controls in place (such as a secondary review of financial statements) in order to help mitigate the inherent risk. You consider the strength of the internal controls when assessing the client's control risk. Your job when assessing inherent risk is to evaluate how susceptible the financial statement assertions are to material misstatement given the nature of the client's business. A few key factors can increase inherent risk.

Environment and external factors: Here are some examples of environment and external factors that can lead to high inherent risk:

Rapid change: A business whose inventory becomes obsolete quickly experiences high inherent risk. **Expiring patents:** Any business in the pharmaceutical industry also has inherently risky environment and external factors. Drug patents eventually expire, which means the company faces competition from other manufacturers marketing the same drug under a generic label.

State of the economy: The general level of economic growth is another external factor affecting all businesses. **Availability of financing:** Another external factor is

interest rates and the associated availability of financing. If your client is having problems meeting its short-term cash payments, available loans with low interest rates may mean the difference between your client staying in business or having to close its doors. Prior-period misstatements: If a company has made mistakes in prior years that weren't material (meaning they weren't significant enough to have to change), those errors still exist in the financial statements. You have to aggregate prior-period misstatements with current year misstatements to see if you need to ask the client to adjust the account for the total misstatement.

You may think an understatement in one year compensates for an overstatement in another year. In auditing, this assumption isn't true. Say you work a cash register and one night the register comes up \$20 short. The next week, you somehow came up \$20 over my draw count. The \$20 differences are added together to represent the total amount of your mistakes which is \$40 and not zero. Zero would indicate no mistakes at all had occurred.

Susceptibility to theft or fraud: If a certain asset is susceptible to theft or fraud, the account or balance level may be considered inherently risky. For example, if a client has a lot of customers who pay in cash, the balance sheet cash account is going to have risk associated with theft or fraud because of the fact that cash is more easily diverted than customer checks or credit card payments.

Looking at industry statistics relating to inventory theft, you may also decide to consider the inventory account as inherently risky. Small inventory items can further increase the risk of this account valuation being incorrect because those items are easier to conceal (and therefore easier to steal).

Control Risk

Control risk has been defined under International Standards of Auditing (ISAs) as following:

The risk that a misstatement that could occur in an assertion about a class of transaction, account balance or disclosure and that could be material, either individually or when aggregated with other misstatements, will not be prevented, or detected and corrected, on a timely basis by the entity's internal control.

In simple words control risk is the probability that a material misstatement exists in an assertion because that misstatement was not either prevented from entering entity's financial information or it was not detected and

corrected by the internal control system of the entity.

It is the responsibility of the management and those charged with governance to implement internal control system and maintain it appropriately which includes managing control risk.

There can be many reasons for control risk to arise and why it cannot be eliminated absolutely. But some of them are as follows:

- Cost-benefit constraints
- Circumvention of controls
- Inappropriate design of controls
- Inappropriate application of controls
- Lack of control environment and accountability
- Novel situations
- Outdated controls
- Inappropriate segregation of duties

Detection Risk

Detection Risk is the risk that the auditors fail to detect a material misstatement in the financial statements. An auditor must apply audit procedures to detect material misstatements in the financial statements whether due to fraud or error. Misapplication or omission of critical audit procedures may result in a material misstatement remaining undetected by the auditor. Some detection risk is always present due to the inherent limitations of the audit such as the use of sampling for the selection of transactions. Detection risk can be reduced by auditors by increasing the number of sampled transactions for detailed testing.

The following answers are incorrect:

Inherent Risk - It is the risk level or exposure of a process or entity to be audited without taking into account the control that management has implemented.

Control Risk - The risk that material error exist that would not be prevented or detected on timely basis by the system of internal controls.

Overall audit risk - The probability that information or financial report may contain material errors and that the auditor may not detect an error that has occurred. An objective in formulating the audit approach is to limit the audit risk in the area under security so the overall audit risk is at sufficiently low level at the completion of the examination.

CISA review manual 2014 page number 50

http://en.wikipedia.org/wiki/Audit_risk

<http://www.dummies.com/how-to/content/how-to-assess-inherent-risk-in-an-audit.html> <http://pakaccountants.com/what-is-control-risk/>

<http://accounting-simplified.com/audit/risk-assessment/audit-risk.html>

QUESTION 22

Which of the following statement INCORRECTLY describes the Control self-assessment (CSA) approach?

- A. CSA is policy or rule driven
- B. CSA Empowered/accountable employees
- C. CSA focuses on continuous improvement/learning curve
- D. In CSA, Staffs at all level, in all functions, are the primary control analyst.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

The word INCORRECTLY is the keyword used in the question. You need to find out an option which incorrectly describes Control Self-assessment.

For your exam you should know the information below about control self-assessment:

Control self-assessment is an assessment of controls made by the staff and management of the unit or units involved. It is a management technique that assures stakeholders, customers and other parties that the internal controls of the organization are reliable.

Benefits of CSA

- Early detection of risk
- More efficient and improved internal controls
- Creation of cohesive teams through employee involvement
- Developing a sense of ownership of the controls in the employees and process owners, and reducing their resistance to control improvement initiatives
- Increased employee awareness of organizational objectives, and knowledge of risk and internal controls
- Highly motivated employees
- Improved audit training process
- Reduction in control cost
- Assurance provided to stakeholders and customers

Traditional and CSA attributes

Traditional Historical CSA

Assign duties/supervises staff Empowered/accountable employees Policy/rule driven Continuous improvement/learning curve
Limited employee participation Extensive employee participation and training Narrow stakeholders focus Broad stakeholders focus
Auditors and other specialist Staff at all level, in all functions, are the primary control analysts

The following answers are incorrect:

The other options specified are correctly describes about CSA.
CISA review manual 2014 page number 61, 62 and 63

QUESTION 23

Which of the following statement INCORRECTLY describes the traditional audit approach in comparison to the Control self-assessment approach?

- A. In traditional approach, Staffs at all level, in all functions, are the primary control analyst.
- B. Traditional approach assigns duties/supervises staff
- C. Traditional approach is a policy driven approach
- D. Traditional approach requires limited employee participations.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

The keyword INCORRECTLY is used in the question. You need to find out an option which incorrectly describes the traditional approach.

For your exam you should know the information below about control self-assessment and traditional approach:

The traditional approach can be summarized as any approach in which the primary responsibility for analyzing and reporting on internal control and risk is assigned to auditor and to lesser extent, controller department and outside consultants.

Control self-assessment is an assessment of controls made by the staff and management of the unit or units involved. It is a management technique that assures stakeholders, customers and other parties that the internal controls of the organization are reliable.

Benefits of CSA

Early detection of risk
More efficient and improved internal controls
Creation of cohesive teams through employee involvement
Developing a sense of ownership of the controls in the employees and process owners, and reducing their resistance to control improvement initiatives
Increased employee awareness of organizational objectives, and knowledge of risk and internal controls Highly motivated employees
Improved audit training process
Reduction in control cost
Assurance provided to stakeholders and customers

Traditional and CSA attributes

Traditional Historical CSA

Assign duties/supervises staff Empowered/accountable employees Policy/rule driven Continuous improvement/learning curve
Limited employee participation Extensive employee participation and training Narrow stakeholders focus Broad stakeholders focus
Auditors and other specialist Staff at all level, in all functions, are the primary control analysts

The following answers are incorrect:

The other options specified are correctly describes about traditional approach.
CISA review manual 2014 page number 61, 62 and 63

QUESTION 24

Which of the following is the most important benefit of control self-assessment (CSA)?

- A. CSA is a policy/rule driven
- B. In CSA approach, risk is identified sooner
- C. CSA requires limited employee participations
- D. In CSA, resources are being used in an effective manner.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Control self-assessment is an assessment of controls made by staff and management within the unit or units involved. It is a management technique that assures stakeholders, customers and other parties that the internal controls of the organization are reliable. The CSA approach requires extensive employee

participations and training. This will help to employee understand more about business risks. This will insure the detection of risk in timely manner.

For your exam you should know the information below about control self-assessment:

Benefits of CSA

Early detection of risk
More efficient and improved internal controls
Creation of cohesive teams through employee involvement
Developing a sense of ownership of the controls in the employees and process owners, and reducing their resistance to control improvement initiatives
Increased employee awareness of organizational objectives, and knowledge of risk and internal controls Highly motivated employees
Improved audit training process
Reduction in control cost
Assurance provided to stakeholders and customers

Traditional and CSA attributes

Traditional Historical CSA

Assign duties/supervises staff Empowered/accountable employees Policy/rule driven Continuous improvement/learning curve
Limited employee participation Extensive employee participation and training Narrow stakeholders focus Broad stakeholders focus
Auditors and other specialist Staff at all level, in all functions, are the primary control analysts

The following answers are incorrect:

The other options specified are incorrectly describes about CSA.
CISA review manual 2014 page number 61, 62 and 63

QUESTION 25

Which of the following testing procedure is used by the auditor during accounting audit to check errors in balance sheet and other financial documentation?

- A. Compliance testing
- B. Sanity testing
- C. Recovery testing
- D. Substantive testing

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

A procedure used during accounting audits to check for errors in balance sheets and other financial documentation. A substantive test might involve checking a random sample of transactions for errors, comparing account balances to find discrepancies, or analysis and review of procedures used to execute and record transactions.

Substantive testing is the stage of an audit when the auditor gathers evidence as to the extent of misstatements in client's accounting records or other information. This evidence is referred to as substantive evidence and is an important factor in determining the auditor's opinion on the financial statements as a whole. The audit procedures used to gather this evidence are referred to as substantive procedures, or substantive tests.

Substantive procedures (or substantive tests) are those activities performed by the auditor during the substantive testing stage of the audit that gather evidence as to the completeness, validity and/or accuracy of

account balances and underlying classes of transactions.

Account balances and underlying classes of transaction must not contain any material misstatements. They must be materially complete, valid and accurate. Auditors gather evidence about these assertions by undertaking substantive procedures, which may include:

Physically examining inventory on balance date as evidence that inventory shown in the accounting records actually exists (validity assertion); Arranging for suppliers to confirm in writing the details of the amount owing at balance date as evidence that accounts payable is complete (completeness assertion); and Making inquiries of management about the collectability of customers' accounts as evidence that trade debtors is accurate as to its valuation. Evidence that an account balance or class of transaction is not complete, valid or accurate is evidence of a substantive misstatement.

The following answers are incorrect:

Compliance Testing - Compliance testing is basically an audit of a system carried out against a known criterion.

Sanity testing - Testing to determine if a new software version is performing well enough to accept it for a major testing effort. If application is crashing for initial use, then system is not stable enough for further testing and build or application is assigned to fix.

Recovery testing Testing how well a system recovers from crashes, hardware failures, or other catastrophic problems.

CISA review manual 2014 page number 52 and 53

<http://www.businessdictionary.com/definition/compliance-test.html>

QUESTION 26

Which of the following testing procedure is used by an auditor to check whether a firm is following the rules and regulations applicable to an activity or practice?

- A. Compliance testing
- B. Sanity testing
- C. Recovery testing
- D. Substantive testing

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

Audit undertaken to confirm whether a firm is following the rules and regulations (prescribed by its internal authority or control system) applicable to an activity or practice.

Compliance testing is basically an audit of a system carried out against a known criterion. A compliance test may come in many different forms dependent on the request received but basically can be broken down into several different types:

Operating Systems and Applications: A verification that an operating system and/or applications are configured appropriately to the companies needs and lockdown requirements, thus providing adequate and robust controls to ensure that the Confidentiality, Integrity and Availability of the system will not be affected in its normal day to day operation.

Systems in development: A verification that the intended system under development meets the configuration and lockdown standards requested by the customer.

Management of IT and Enterprise Architecture: A verification that the in-place IT management infrastructure encompassing all aspects of system support has been put in place. This is to ensure effective change control, audit, business continuity and security procedures etc. have been formulated, documented and put in place. Interconnection Policy: A verification that adequate security and business continuity controls governing the connection to other systems, be they Telecommunications, Intranets, Extranets and Internet etc. have been put in place, have been fully documented and correspond to the stated customer requirements.

The following answers are incorrect:

Substantive testing - A procedure used during accounting audits to check for errors in balance sheets and other financial documentation. A substantive test might involve checking a random sample of transactions for errors, comparing account balances to find discrepancies, or analysis and review of procedures used to execute and record transactions.

Sanity testing - Testing to determine if a new software version is performing well enough to accept it for a major testing effort. If application is crashing for initial use, then system is not stable enough for further testing and build or application is assigned to fix.

Recovery testing Testing how well a system recovers from crashes, hardware failures, or other catastrophic problems.

CISA review manual 2014 page number 52 and 53

<http://www.wikijob.co.uk/wiki/substantive-testing>

QUESTION 27

What are the different types of Audits?

- A. Compliance, financial, operational, forensic and integrated
- B. Compliance, financial, operational, G9 and integrated
- C. Compliance, financial, SA1, forensic and integrated
- D. Compliance, financial, operational, forensic and capability

Correct Answer: A
Explanation

Explanation/Reference:

Section: The process of Auditing Information System
 Compliance, financial, operational, forensic and integrated are different types of audit.

For your exam you should know the information below:

What is an audit?

An audit in general terms is a process of evaluating an individual or organization's accounts. This is usually done by an independent auditing body. Thus, audit involves a competent and independent person obtaining evidence and evaluating it objectively with regard to a given entity, which in this case is the subject of audit, in order to establish conformance to a given set of standards. Audit can be on a person, organization, system, enterprise, project or product.

Compliance Audit

A compliance audit is a comprehensive review of an organization's adherence to regulatory guidelines. Independent accounting, security or IT consultants evaluate the strength and thoroughness of compliance preparations. Auditors review security policies, user access controls and risk management procedures over the course of a compliance audit. Compliance audit include specific tests of controls to demonstrate adherence to specific regulatory or industry standard. These audits often overlap traditional audits, but may focus on

particular system or data.

What, precisely, is examined in a compliance audit will vary depending upon whether an organization is a public or private company, what kind of data it handles and if it transmits or stores sensitive financial data. For instance, SOX requirements mean that any electronic communication must be backed up and secured with reasonable disaster recovery infrastructure. Health care providers that store or transmit e-health records, like personal health information, are subject to HIPAA requirements. Financial services companies that transmit credit card data are subject to PCI DSS requirements. In each case, the organization must be able to demonstrate compliance by producing an audit trail, often generated by data from event log management software.

Financial Audit

A financial audit, or more accurately, an audit of financial statements, is the verification of the financial statements of a legal entity, with a view to express an audit opinion. The audit opinion is intended to provide reasonable assurance, but not absolute assurance, that the financial statements are presented fairly, in all material respects, and/or give a true and fair view in accordance with the financial reporting framework. The purpose of an audit is to provide an objective independent examination of the financial statements, which increases the value and credibility of the financial statements produced by management, thus increase user confidence in the financial statement, reduce investor risk and consequently reduce the cost of capital of the preparer of the financial statements.

Operational Audit

Operational Audit is a systematic review of effectiveness, efficiency and economy of operation. Operational audit is a future-oriented, systematic, and independent evaluation of organizational activities. In Operational audit financial data may be used, but the primary sources of evidence are the operational policies and achievements related to organizational objectives. Operational audit is a more comprehensive form of an Internal audit.

The Institute of Internal Auditor (IIA) defines Operational Audit as a systematic process of evaluating an organization's effectiveness, efficiency and economy of operations under management's control and reporting to appropriate persons the results of the evaluation along with recommendations for improvement.

Objectives

To appraise the effectiveness and efficiency of a division, activity, or operation of the entity in meeting organizational goals.

To understand the responsibilities and risks faced by an organization. To identify, with management participation, opportunities for improving control. To provide senior management of the organization with a detailed understanding of the Operations.

Integrated Audits

An integrated audit combines financial and operational audit steps. An integrated audit is also performed to assess overall objectives within an organization, related to financial information and asset, safeguarding, efficiency and or internal auditors and would include compliance test of internal controls and substantive audit step.

IS Audit

An information technology audit, or information systems audit, is an examination of the management controls within an Information technology (IT) infrastructure. The evaluation of obtained evidence determines if the information systems are safeguarding assets, maintaining data integrity, and operating effectively to achieve the organization's goals or objectives. These reviews may be performed in conjunction with a financial statement audit, internal audit, or other form of attestation engagement.

The primary functions of an IT audit are to evaluate the systems that are in place to guard an organization's information. Specifically, information technology audits are used to evaluate the organization's ability to protect its information assets and to properly dispense information to authorized parties. The IT audit aims to evaluate the following:

Will the organization's computer systems be available for the business at all times when required? (known as availability) Will the information in the systems be disclosed only to authorized users? (known as security and

confidentiality) Will the information provided by the system always be accurate, reliable, and timely? (measures the integrity) In this way, the audit hopes to assess the risk to the company's valuable asset (its information) and establish methods of minimizing those risks.

Forensic Audit

Forensic audit is the activity that consists of gathering, verifying, processing, analyzing of and reporting on data in order to obtain facts and/or evidence - in a predefined context - in the area of legal/financial disputes and or irregularities (including fraud) and giving preventative advice.

The purpose of a forensic audit is to use accounting procedures to collect evidence for the prosecution or investigation of financial crimes such as theft or fraud. Forensic audits may be conducted to determine if wrongdoing occurred, or to gather materials for the case against an alleged criminal.

The following answers are incorrect:

Compliance, financial, operational, forensic and integrated are different types of audits. G9, SA1 and capability are not the audit types.

CISA Review Manual 2014 Page number 47

<http://searchcompliance.techtarget.com/definition/compliance-audit> http://en.wikipedia.org/wiki/Financial_audit

http://en.wikipedia.org/wiki/Operational_auditing

http://en.wikipedia.org/wiki/Information_technology_audit

http://www.investorwords.com/16445/forensic_audit.html

QUESTION 28

Statistical sampling is NOT based on which of the following audit sample techniques?

- A. Haphazard Sampling

- B. Random Sampling
- C. Cell Sampling
- D. Fixed interval sampling

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

The NOT keyword is used in the question. You need find out an option which is NOT an example of statistical sampling. Statistical sampling is NOT based on Haphazard sampling.

For your exam you should know the information below

Audit samples are selected for the purpose of collecting representative evidence to be subjected to either compliance testing or substantive testing. The auditor should consider a selection technique that will provide the most relevant evidence supported by appropriate analytical procedures. Two basic types of audit samples can be designed by the auditor to fulfill their requirements:

statistical and no statistical. Below Figure shows the various audit samples, as well as their testing methods. Care is given to the selection process in order to avoid drawing the wrong conclusion from the wrong sample. This is referred to as a sampling risk. Let's look at each of these samples more closely.

Statistical Sampling

Statistical sampling uses mathematical techniques that result in an outcome that is mathematically quantifiable. Statistical samples are usually presented as a percentage. The purpose of statistical sampling is to gain an objective representation. Samples are selected by an objective mathematical process. The auditor should be aware that if the client has strong internal controls, the sample sizes may be smaller because the

odds of fraud or failure will be lower.

Examples of statistical sampling include the following:

Random sampling Samples are selected at random.

Cell sampling Random selection is performed at predefined intervals. **Fixed interval sampling** The sample existing at every $n + 1$ interval increment is selected for testing.

No statistical Sampling

No statistical sampling is based on the auditor's judgment (also referred to as judgmental sampling). The auditor determines the sample size, the method of generating the sample, and the number of items to be analyzed. The results of judgmental sampling are unlikely to represent the actual population. This is a subjective process usually based on elements of risk or materiality. An example of no statistical sampling includes haphazard sampling, in which the samples are randomly drawn for testing. After the samples are selected, the next step is to perform compliance tests or substantive testing. Conducting Audit Testing As stated earlier, the basic test methods used will be either compliance testing or substantive testing. Appropriate audit samples will have to be generated for the test.

Compliance Testing

Compliance testing tests for the presence or absence of something. Compliance testing includes verifying that policies and procedures have been put in place, and checking that user access rights, program change control procedures, and system audit logs have been activated. An example of a compliance test is comparing the list of persons with physical access to the data center against the HR list of current employees. Compliance testing is based on one of the following types of audit samples:

Attribute sampling Generally popular in compliance testing. The objective is to determine whether an attribute is present or absent in the subject sample. The result is specified by the rate of occurrence--for example, the presence of 1 in 100 units would be 1 percent.

Stop-and-go sampling Used when few errors are expected. Stop-and-go allows the test to occur without excessive effort in sampling and provides the opportunity to stop testing at the earliest possible opportunity. It is a simple form of testing to reinforce any claim that errors are unlikely in the sample population.

Discovery sampling A 100 percent sampling used to detect fraud or when the likelihood of evidence existing is low. Forensics is an excellent example of discovery sampling. This is an attempt to discover evidence. Precision, or expected error rate The precision rate indicates the acceptable margin of error between audit samples and the total quantity of the subject population. This is usually expressed as a percentage, such as 5 percent. To obtain a very low error rate, it is necessary to use a very large sample in testing. Auditors are justified in using a smaller sample size when the total population is expected to be error-free. A larger sample is required when errors are expected to be present in the population. The larger sample can yield a higher average. When errors are expected, the auditor must examine more data to determine whether the actual errors are within a tolerable error rate (maximum errors you would accept). Error levels may be determined by reviewing the findings of a prior audit and by considering changes in the organization's procedures. Use the risk-based audit strategy to determine whether your samples and tests are telling the truth about the audited.

Substantive Testing

Substantive testing seeks to verify the content and integrity of evidence. Substantive tests may include complex calculations to verify account balances, perform physical inventory counts, or execute sample transactions to verify the accuracy of supporting documentation. Substantive tests use audit samples selected by dollar value or to project (forecast or estimate) a total for groups with related characteristics.

Substantive testing is based on one of the following types of audit samples:

Variable sampling Used to designate dollar values or weights (effectiveness) of an entire subject population by prorating from a smaller sample. Consider the challenge of counting large volumes of currency by its weight. Variable sampling could be used to count currency by multiplying the physical weight of one unit by the total weight of the combined sample, and then multiplying by the face value printed on the bill or coin. A demonstration is a single \$50 bill weighing 1.0 gram, with the entire sample of \$50 bills weighing 61 grams altogether. The combined sample weight would indicate a total quantity of 61 bills for an estimated dollar value

of \$3,050. This is a common technique for forecasting quantity and value of inventory based on particular characteristics.

Unsatisfied mean estimation Used in an attempt to project an estimated total for the whole subject population. **Stratified mean estimation** Used to calculate an average by group, similar to demographics, whereby the entire population is divided (stratified) into smaller groups based on similar characteristics. Examples are teenagers from the ages of 13 to 19, people from the ages of 20 to 29, people from the ages of 30 to 39, and those who are male or female, smokers or nonsmokers, and so on. **Difference estimation** Used to determine the difference between audited and unaudited claims of value.

The following answers are incorrect:

The other options like Random Sampling, Cell Sampling and Fixed Interval Sampling are examples of Statistical sampling.

CISA review manual 2014 page number 55 to 56

CISA certified information system auditor study guide Second Edition Page Number 98 to 101

QUESTION 29

An organization performs nightly backups but does not have a formal policy. An IS auditor should FIRST:

- A. evaluate current backup procedures
- B. escalate to senior management
- C. document a policy for the organization
- D. recommend automated backup

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 30

An IS auditor reviewing an organization's data privacy controls observes that privacy notices do not clearly state how the organization uses customer data for its processing operations. Which of the following data protection principles **MUST** be implemented to address this gap?

- A. Maintenance of data integrity
- B. Access to collected data
- C. Retention of consent documentation
- D. Purpose for data collection

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 31

An IS auditor discovers that validation controls in a web application have been moved from the server side into the browser to boost performance. This would **MOST** likely increase the risk of a successful attack by:

- A. phishing
- B. structured query language (SQL) injection
- C. denial of service (DoS)
- D. buffer overflow

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 32

In a follow-up audit, an IS auditor notes that management has addressed the original findings in a different way than originally agreed upon. The auditor should **FIRST**:

- A. mark the recommendation as satisfied and close the finding
- B. verify if management's action mitigates the identified risk
- C. re-perform the audit to assess the changed control environment
- D. escalate the deviation to the audit committee

Correct Answer: D

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 33

An organization is considering outsourcing the processing of customer insurance claims. An IS auditor notes that customer data will be sent offshore for processing. Which of the following would be the **BEST** way to address the risk of exposing customer data?

- A. Require background checks on all service provider personnel involved in the processing of data.
- B. Recommend the use of a service provider within the same country as the organization.
- C. Consider whether the service provider has the ability to meet service level agreements (SLAs).
- D. Assess whether the service provider meets the organization's data protection policies.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 34

An IS audit team is evaluating the documentation related to the most recent application user-access review performed by IT and business management. It is determined the user list was not system-generated. Which of the following should be the **GREATEST** concern?

- A. Source of the user list reviewed
- B. Availability of the user list reviewed
- C. Confidentiality of the user list reviewed
- D. Completeness of the user list reviewed

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 35

Which of the following should an IS auditor determine **FIRST** when evaluating additional hardware required to support the acquisition of a new accounting system?

- A. A training program has been developed to support the new accounting system.
- B. The supplier has experience supporting accounting systems.
- C. The hardware specified will be compliant with the current IT strategy.
- D. The hardware will be installed in a secure and environmentally controlled area.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 36

A company requires that all program change requests (PCRs) be approved and all modifications be automatically logged. Which of the following IS audit procedures will BEST determine whether unauthorized changes have been made to production programs?

- A. Review a sample of PCRs for proper approval throughout the program change process.
- B. Trace a sample of program changes from the log to completed PCR forms.
- C. Use source code comparison software to determine whether any changes have been made to a sample of programs since the last audit date.
- D. Trace a sample of complete PCR forms to the log of all program changes.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 37

An IS auditor submitted audit reports and scheduled a follow-up audit engagement with a client. The client has requested to engage the services of the same auditor to develop enhanced controls. What is the GREATEST concern with this request?

- A. It would require the approval of the audit manager.
- B. It would be beyond the original audit scope.
- C. It would a possible conflict of interest.
- D. It would require a change to the audit plan.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 38

An IS auditor is evaluating the completeness of privacy procedures involving personally identifiable information (PII). Which of the following is MOST important for the auditor to verify is included in the procedures?

- A. Regulatory requirements for protecting PII
- B. The organization's definition of PII
- C. Encryption requirements for transmitting PII externally
- D. A description of how PII is masked within key systems

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 39

The risk that the IS auditor will not find an error that has occurred is identified by which of the following terms?

- A. Control
- B. Prevention
- C. Inherent
- D. Detection

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 40

An IS auditor finds that application servers had inconsistent security settings leading to potential vulnerabilities. Which of the following is the BEST recommendation by the IS auditor?

- A. Improve the change management process
- B. Perform a configuration review
- C. Establish security metrics
- D. Perform a penetration test

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 41

An IS auditor reviewing a new application for compliance with information privacy principles should be the MOST concerned with:

- A. nonrepudiation
- B. collection limitation
- C. availability
- D. awareness

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 42

Which of the following is the PRIMARY reason for an IS auditor to issue an interim audit report?

- A. To avoid issuing a final audit report
- B. To enable the auditor to complete the engagement in a timely manner
- C. To provide feedback to the auditee for timely remediation
- D. To provide follow-up opportunity during the audit

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 43

Which of the following conditions would be of MOST concern to an IS auditor assessing the risk of a successful brute force attack encrypted data at rest?

- A. Use of symmetric encryption
- B. Use of asymmetric encryption
- C. Random key generation
- D. Short key length

Correct Answer: D

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 44

In which of the following SDLC phases would the IS auditor expect to find that controls have been incorporated into system specifications?

- A. Development
- B. Implementation
- C. Design
- D. Feasibility

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 45

An IS auditor has been invited to join an IT project team responsible for building and deploying a new digital customer marketing platform. Which of the following is the BEST way for the auditor to support this project while maintaining independence?

- A. Develop selection criteria for potential digital technology vendors.
- B. Conduct an industry peer benchmarking exercise and advise on alternative solutions.
- C. Conduct a risk assessment of the proposed initiative.
- D. Design controls based on current regulatory requirements for digital technologies.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 46

An IS auditor observes a system performance monitoring tool which states that a server critical to the organization averages high CPU utilization across a cluster of four virtual servers throughout the audit period. To determine if further investigation is required, an IS auditor should review:

- A. the system process activity log
- B. system baselines
- C. the number of CPUs allocated to each virtual machine
- D. organizational objectives

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 47

An IS auditor has discovered that a cloud-based application was not included in an application inventory that was used to confirm the scope of an audit. The business process owner explained that the application will be audited by a third party in the next year. The auditor's NEXT step should be to:

- A. evaluate the impact of the cloud application on the audit scope
- B. revise the audit scope to include the cloud-based application
- C. review the audit report when performed by the third party
- D. report the control deficiency to senior management

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 48

Which of the following should MOST concern an IS auditor reviewing an intrusion detection system (IDS)?

- A. Number of false negatives
- B. Number of false positives
- C. Legitimate traffic blocked by the system
- D. Reliability of IDS logs

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 49

Multiple invoices are usually received for individual purchase orders, since purchase orders require staggered delivery dates. Which of the following is the BEST audit technique to test for duplicate payments?

- A. Run the data on the software programs used to process supplier payments.
- B. Use generalized audit software on the invoice transaction file.
- C. Run the data on the software programs used to process purchase orders.
- D. Use generalized audit software on the purchase order transaction file.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 50

An IS auditor considering the risks associated with spooling sensitive reports for off-line printing will be the MOST concerned that:

- A. data can easily be read by operators
- B. data can more easily be amended by unauthorized persons
- C. unauthorized copies of reports can be printed
- D. output will be lost if the system should fail

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 51

In a data center audit, an IS auditor finds that the humidity level is very low. The IS auditor would be MOST concerned because of an expected increase in:

- A. employee discomfort
- B. risk of fire
- C. static electricity problems
- D. backup tape failures

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 52

Before concluding that internal controls can be relied upon, the IS auditor should:

- A. discuss the internal control weaknesses with the auditee
- B. document application controls
- C. conduct tests of compliance
- D. document the system of internal control

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 53

The IS auditor has identified a potential fraud perpetrated by the network administrator. The IS auditor should:

- A. issue a report to ensure a timely resolution
- B. review the audit finding with the audit committee prior to any other discussions
- C. perform more detailed tests prior to disclosing the audit results
- D. share the potential audit finding with the security administrator

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 54

Which of the following should an IS auditor review FIRST when planning a customer data privacy audit?

- A. Legal and compliance requirements
- B. Customer agreements
- C. Organizational policies and procedures
- D. Data classification

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 55

Which of the following should be of MOST concern to an IS auditor reviewing the public key infrastructure (PKI) for enterprise e-mail?

- A. The private key certificate has not been updated.
- B. The certificate revocation list has not been updated.
- C. The certificate practice statement has not been published.
- D. The PKI policy has not been updated within the last year.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 56

Which of the following should be established FIRST when initiating a control self-assessment program in a small organization?

- A. Control baselines
- B. Client questionnaires
- C. External consultants
- D. Facilitated workshops

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 57

What is an IS auditor's BEST course of action if informed by a business unit's representatives that they are too busy to cooperate with a scheduled audit?

- A. Reschedule the audit for a time more convenient to the business unit.
- B. Notify the chief audit executive who can negotiate with the head of the business unit.
- C. Begin the audit regardless and insist on cooperation from the business unit.
- D. Notify the audit committee immediately and request they direct the audit begin on schedule.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 58

An IS auditor has completed an audit of an organization's accounts payable system. Which of the following should be rated as the HIGHEST risk in the audit report and requires immediate remediation?

- A. Lack of segregation of duty controls for reconciliation of payment transactions
- B. Lack of segregation of duty controls for removal of vendor records
- C. Lack of segregation of duty controls for updating the vendor master file
- D. Lack of segregation of duty controls for reversing payment transactions

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 59

An IS auditor is planning on utilizing attribute sampling to determine the error rate for health care claims processed. Which of the following factors will cause the sample size to decrease?

- A. Population size increase
- B. Expected error rate increase
- C. Acceptable risk level decrease
- D. Tolerable error rate increase

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 60

Which of the following is the PRIMARY benefit of using an integrated audit approach?

- A. Higher acceptance of the findings from the audited business areas
- B. The avoidance of duplicated work and redundant recommendations
- C. Enhanced allocation of resources and reduced audit costs
- D. A holistic perspective of overall risk and a better understanding of controls

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 61

Which of the following is an analytical review procedure for a payroll system?

- A. Performing penetration attempts on the payroll system
- B. Evaluating the performance of the payroll system using benchmarking software
- C. Performing reasonableness tests by multiplying the number of employees by the average wage rate
- D. Testing hours reported on time sheets

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 62

An IS auditor observes that the CEO has full access to the enterprise resource planning (ERP) system. The IS auditor should FIRST:

- A. accept the level of access provided as appropriate
- B. recommend that the privilege be removed
- C. ignore the observation as not being material to the review
- D. document the finding as a potential risk

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 63

Two servers are deployed in a cluster to run a mission-critical application. To determine whether the system has been designed for optimal efficiency, the IS auditor should verify that:

- A. the security features in the operating system are all enabled
- B. the number of disks in the cluster meets minimum requirements
- C. the two servers are of exactly the same configuration
- D. load balancing between the servers has been implemented

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 64

The GREATEST risk when performing data normalization is:

- A. the increased complexity of the data model
- B. duplication of audit logs
- C. reduced data redundancy
- D. decreased performance

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 65

An IS auditor has found that a vendor has gone out of business and the escrow has an older version of the source code. What is the auditor's BEST recommendation for the organization?

- A. Continue using the existing application since it meets the current requirements
- B. Prepare a maintenance plan that will support the application using the existing code
- C. Bring the escrow version up to date
- D. Undertake an analysis to determine the business risk

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 66

Which of the following is the BEST way to evaluate the effectiveness of access controls to an internal network?

- A. Perform a system penetration test
- B. Test compliance with operating procedures
- C. Review access rights
- D. Review router configuration tables

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 67

An IS auditor finds a number of system accounts that do not have documented approvals. Which of the following should be performed FIRST by the auditor?

- A. Have the accounts removed immediately
- B. Obtain sign-off on the accounts from the application owner
- C. Document a finding and report an ineffective account provisioning control
- D. Determine the purpose and risk of the accounts

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 68

An IS auditor is a member of an application development team that is selecting software. Which of the following would impair the auditor's independence?

- A. Verifying the weighting of each selection criteria
- B. Approving the vendor selection methodology
- C. Reviewing the request for proposal (RFP)
- D. Witnessing the vendor selection process

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 69

An internal control audit has revealed a control deficiency related to a legacy system where the compensating controls no longer appear to be effective. Which of the following would BEST help the information security manager determine the security requirements to resolve the control deficiency?

- A. Cost-benefit analysis
- B. Gap analysis
- C. Risk assessment
- D. Business case

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 70

An audit of the quality management system (QMS) begins with an evaluation of the:

- A. organization's QMS policy
- B. sequence and interaction of QMS processes
- C. QMS processes and their application
- D. QMS document control procedures

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 71

An IS auditor has completed an audit on the organization's IT strategic planning process. Which of the following findings should be given the HIGHEST priority?

- A. The IT strategic plan was completed prior to the formulation of the business strategic plan
- B. Assumptions in the IT strategic plan have not been communicated to business stakeholders
- C. The IT strategic plan was formulated based on the current IT capabilities
- D. The IT strategic plan does not include resource requirements for implementation

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 72

Which of the following provides the BEST evidence of successfully completed batch uploads?

- A. Sign-off on the batch journal
- B. Using sequence controls

- C. Enforcing batch cut-off times
- D. Reviewing process logs

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 73

An IS auditor is conducting a review of a healthcare organization's IT policies for handling medical records. Which of the following is MOST important to verify?

- A. A documented policy approval process is in place
- B. Policy writing standards are consistent
- C. The policies comply with regulatory requirements
- D. IT personnel receive ongoing policy training

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 74

Audit management has just completed the annual audit plan for the upcoming year, which consists entirely of high-risk processes. However, it is determined that there are insufficient resources to execute the plan. What should be done NEXT?

- A. Remove audits from the annual plan to better match the number of resources available
- B. Reduce the scope of the audits to better match the number of resources available
- C. Present the annual plan to the audit committee and ask for more resources
- D. Review the audit plan and defer some audits to the subsequent year

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 75

If concurrent update transactions to an account are not processed properly, which of the following will be affected?

- A. Integrity
- B. Confidentiality
- C. Availability
- D. Accountability

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 76

When conducting a review of security incident management, an IS auditor found there are no defined escalation processes. All incidents are managed by the service desk. Which of the following should be the auditor's PRIMARY concern?

- A. Inefficient use of service desk resources
- B. Management's lack of awareness of high impact incidents
- C. Delays in resolving low priority trouble tickets
- D. Management's inability to follow up on incident resolution

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 77

Which of the following should an IS auditor be MOST concerned with during a post-implementation review?

- A. The system does not have a maintenance plan
- B. The system contains several minor defects
- C. The system was over budget by 15%
- D. The system deployment was delayed by three weeks

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 78

An IS auditor is reviewing a bank's service level agreement (SLA) with a third-party provider that hosts the bank's secondary data center. Which of the following findings should be of GREATEST concern to the auditor?

- A. The recovery point objective (RPO) has a shorter duration than documented in the disaster recovery plan
- B. The recovery time objective (RTO) has a longer duration than documented in the disaster recovery plan

- C. Backup data is hosted online only
- D. The SLA has not been reviewed in more than a year

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 79

Which of the following is the MOST appropriate responsibility of an IS auditor involved in a data center renovation project?

- A. Performing independent reviews of responsible parties engaged in the project
- B. Ensuring the project progresses as scheduled and milestones are achieved
- C. Performing day-to-day activities to ensure the successful completion of the project
- D. Providing sign off on the design of controls for the data center

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 80

Which of the following is MOST important for an IS auditor to determine when reviewing how the organization's incident response team handles devices that may be involved in criminal activity?

- A. Whether devices are checked for malicious applications
- B. Whether the access logs are checked before seizing the devices
- C. Whether users have knowledge of their devices being examined
- D. Whether there is a chain of custody for the devices

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 81

During a follow-up audit, an IS auditor learns the organization implemented an automated process instead of the originally agreed upon enhancement of the manual process. The auditor should:

- A. report the finding that recommendations were not acted upon
- B. perform a cost-benefit analysis on the new process
- C. verify that the new process satisfies control objectives
- D. report the recommendation as implemented

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 82

During a privileged access review, an IS auditor observes many help desk employees have privileges within systems not required for their job functions. Implementing which of the following would have prevented this situation?

- A. Separation of duties
- B. Multi-factor authentication
- C. Least privilege access
- D. Privileged access reviews

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 83

Management disagrees with a finding in a draft audit report and provides supporting documentation. Which of the following should be the IS auditor's NEXT course of action?

- A. Document management's disagreement in the final report
- B. Evaluate the supporting documentation
- C. Escalate the issue with supporting documentation to senior management
- D. Finalize the draft audit report without changes

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 84

Which of the following audit techniques is MOST appropriate for verifying application program controls?

- A. Statistical sampling
- B. Code review

- C. Confirmation of accounts
- D. Use of test data

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 85

A business has requested an IS audit to determine whether information stored in an application system is adequately protected. Which of the following is the MOST important action before the audit work begins?

- A. Establish control objectives
- B. Conduct a vulnerability analysis
- C. Perform penetration testing
- D. Review remediation reports

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 86

Which audit technique provides the GREATEST assurance that incident management procedures are effective?

- A. Determining whether incidents are categorized and addressed
- B. Performing comprehensive vulnerability scanning and penetration testing
- C. Comparing incident management procedures to best practices
- D. Evaluating end-user satisfaction survey results

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 87

Which of the following findings would be of MOST concern to an IS auditor performing a review of an end-user developed application that generates financial statements?

- A. The application is not sufficiently supported by the IT department
- B. There is not adequate training in the use of the application
- C. There is no adequate user license for the application
- D. There is no control to ensure accuracy of the processed data

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 88

An organization plans to deploy Wi-Fi location analytics to count the number of shoppers per day across its various retail outlets. What should the IS auditor recommend as the FIRST course of action by IT management?

- A. Conduct a privacy impact assessment
- B. Mask media access control (MAC) addresses
- C. Survey shoppers for feedback
- D. Develop a privacy notice to be displayed to shoppers

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 89

An IS auditor discovered abnormalities in a monthly report generated from a system upgraded six months ago. Which of the following should be the auditor's FIRST course of action?

- A. Inspect source code for proof of abnormalities
- B. Perform a change management review of the system
- C. Schedule an access review of the system
- D. Determine the impact of abnormalities in the report

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 90

When auditing the effectiveness of a biometric system, which of the following indicators would be MOST important to review?

- A. False negatives
- B. False acceptance rate
- C. Failure to enroll rate
- D. System response time

Correct Answer: B
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 91

An IS auditor conducting audit follow-up activities learns that some previously agreed-upon corrective actions have not been taken and that the associated risk has been accepted by senior management. If the auditor disagrees with management's decision, what is the BEST way to address the situation?

- A. Repeat the audit with audit scope only covering areas with accepted risks
- B. Report the issue to the chief audit executive for resolution
- C. Recommend new corrective actions to mitigate the accepted risk
- D. Take no action since management's decision has been made

Correct Answer: B
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 92

During a security audit, an IS auditor is tasked with reviewing log entries obtained from an enterprise intrusion prevention system (IPS). Which type of risk would be associated with the potential for the auditor to miss a sequence of logged events that could indicate an error in the IPS configuration?

- A. Inherent risk
- B. Sampling risk
- C. Control risk
- D. Detection risk

Correct Answer: D
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 93

An organization is concerned about duplicate vendor payments on a complex system with a high volume of transactions. Which of the following would be MOST helpful to an IS auditor to determine whether duplicate vendor payments exist?

- A. Computer-assisted technique
- B. Stop-and-go testing
- C. Statistical sampling
- D. Judgmental sampling

Correct Answer: A
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 94

The MAIN benefit of using an integrated test facility (ITF) as an online auditing technique is that it enables:

- A. a cost-effective approach to application controls audit
- B. auditors to investigate fraudulent transactions
- C. auditors to test without impacting production data
- D. the integration of financial and audit tests

Correct Answer: C
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 95

When evaluating the ability of a disaster recovery plan (DRP) to enable the recovery of IT processing capabilities, it is MOST important for the IS auditor to verify the plan is:

- A. stored at an offsite location
- B. communicated to department heads
- C. regularly reviewed
- D. periodically tested

Correct Answer: C
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 96

An IS auditor is analyzing a sample of accesses recorded on the system log of an application. The auditor intends to launch an intensive investigation if one exception is found. Which sampling method would be appropriate?

- A. Discovery sampling
- B. Variable sampling
- C. Stratified sampling
- D. Judgmental sampling

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 97

Assessments of critical information systems are based on a cyclical audit plan that has not been updated for several years. Which of the following should the IS auditor recommend to BEST address this situation?

- A. Use a revolving set of audit plans to cover all systems
- B. Update the audit plan quarterly to account for delays and deferrals of periodic reviews
- C. Regularly validate the audit plan against business risks
- D. Do not include periodic reviews in detail as part of the audit plan

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 98

An IS auditor is assessing risk associated with peer-to-peer file sharing within an organization. Which of the following should be of GREATEST concern?

- A. File-sharing policies have not been reviewed since last year
- B. Only some employees are required to attend security awareness training
- C. Not all devices are running antivirus programs
- D. The organization does not have an efficient patch management process

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 99

An IS auditor is reviewing an organization's incident management processes and procedures. Which of the following observations should be the auditor's GREATEST concern?

- A. Ineffective incident classification
- B. Ineffective incident prioritization
- C. Ineffective incident detection
- D. Ineffective post-incident review

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 100

During an IS audit, it is discovered that security configurations differ across the organization's virtual server farm. Which of the following is the IS auditor's BEST recommendation for improving the control environment?

- A. Conduct an independent review of each server's security configuration
- B. Implement a security configuration baseline for virtual servers
- C. Implement security monitoring controls for high-risk virtual servers
- D. Conduct a standard patch management review across the virtual server farm

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 101

A senior auditor is reviewing work papers prepared by a junior auditor indicating that a finding was removed after the auditee said they corrected the problem. Which of the following is the senior auditor's MOST appropriate course of action?

- A. Approve the work papers as written
- B. Refer the issue to the audit director
- C. Have the finding reinstated
- D. Ask the auditee to retest

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 102

An IS auditor is conducting a pre-implementation review to determine a new system's production readiness.

The auditor's PRIMARY concern should be whether:

- A. the project adhered to the budget and target date
- B. users were involved in the quality assurance (QA) testing
- C. there are unresolved high-risk items
- D. benefits realization has been evidenced

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 103
An IS auditor reviewing the threat assessment for a data center would be MOST concerned if:

- A. all identified threats relate to external entities
- B. some of the identified threats are unlikely to occur
- C. neighboring organizations' operations have been included
- D. the exercise was completed by local management

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 104
When following up on a data breach, an IS auditor finds a system administrator may have compromised the chain of custody. Which of the following should the system administrator have done FIRST to preserve the evidence?

- A. Perform forensic discovery
- B. Notify key stakeholders
- C. Quarantine the system
- D. Notify the incident response team

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 105
Which of the following should an IS auditor verify when auditing the effectiveness of virus protection?

- A. Frequency of IDS log reviews
- B. Currency of software patch application
- C. Schedule for migration to production
- D. Frequency of external Internet access

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 106
Which of the following should be reviewed FIRST when planning an IS audit?

- A. Recent financial information
- B. Annual business unit budget
- C. IS audit standards
- D. The business environment

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 107
An IS auditor is evaluating a virtual server environment and learns that the production server, development server, and management console are housed in the same physical host. What should be the auditor's PRIMARY concern?

- A. The physical host is a single point of failure
- B. The management console is a single point of failure
- C. The development server and management console share the same host
- D. The development and production servers share the same host

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 108
An organization's disposal policy emphasizes obtaining maximum value for surplus IT media. The IS auditor should obtain assurance that:

- A. the media is returned to the vendor for credit
- B. any existing data is removed before disposal
- C. identification labels are removed
- D. the media is recycled to other groups within the organization

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 109

An auditor notes the administrator user ID is shared among three financial managers to perform month-end updates. Which of the following is the BEST recommendation to ensure the administrator ID in the financial system is controlled effectively?

- A. Implement use of individual software tokens
- B. Conduct employee awareness training
- C. Institute user ID logging and monitoring
- D. Ensure data in the financial systems has been classified

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 110

Which of the following is MOST important for an IS auditor to verify after finding repeated unauthorized access attempts were recorded on a security report?

- A. Password reset requests have been confirmed as legitimate
- B. There is evidence that the incident was investigated
- C. System configuration changes are properly tracked
- D. A comprehensive access policy has been established

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 111

An IS auditor is involved with a project and finds an IT project stakeholder wants to make a change that could affect both the project scope and schedule. Which of the following would be the MOST appropriate action for the project manager with respect to the change request?

- A. Recommend to the project sponsor whether to approve the change
- B. Modify the project plan as a result of the change
- C. Evaluate the impact of the change
- D. Ignore out-of-scope requests

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 112

Which of the following should an IS auditor expect to see in a network vulnerability assessment?

- A. Misconfiguration and missing updates
- B. Malicious software and spyware
- C. Security design flaws
- D. Zero-day vulnerabilities

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 113

An IS auditor is evaluating the security of an organization's data backup process, which includes the transmission of daily incremental backups to a dedicated offsite server. Which of the following findings poses the GREATEST risk to the organization?

- A. Backup transmissions are not encrypted
- B. Backup transmissions occasionally fail
- C. Data recovery testing is conducted once per year
- D. The archived data log is incomplete

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 114

When continuous monitoring systems are being implemented, an IS auditor should FIRST identify:

- A. the location and format of output files
- B. applications that provide the highest financial risk
- C. high-risk areas within the organization
- D. the controls on which to focus

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 115

During a follow-up audit, an IS auditor concludes that a previously identified issue has not been adequately remediated. The auditee insists the risk has been addressed. The auditor should:

- A. recommend an independent assessment by a third party
- B. report the disagreement according to established procedures
- C. follow-up on the finding next year
- D. accept the auditee's position and close the finding

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 116

An organization allows employee use of personal mobile devices for corporate email. Which of the following should be the GREATEST IS audit concern?

- A. Email forwarding to private devices requires excessive network bandwidth
- B. There is no corporate policy for the acceptable use of private devices
- C. There is no adequate tracking of the working time spent out-of-hours
- D. The help desk is not able to fully support different kinds of private devices

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 117

Which of the following findings would be of GREATEST concern to an IS auditor reviewing an organization's newly implemented online security awareness program?

- A. Only new employees are required to attend the program
- B. The timing for program updates has not been determined
- C. Metrics have not been established to assess training results
- D. Employees do not receive immediate notification of results

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 118

What would be of GREATEST concern to an IS auditor observing shared key cards being utilized to access an organization's data center?

- A. The lack of a multi-factor authentication system
- B. The inability to identify who has entered the data center
- C. The inability to track the number of misplaced cards
- D. The lack of enforcement of organizational policy and procedures

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 119

Which of the following is MOST important for an IS auditor to ensure is included in a global organization's online data privacy notification to customers?

- A. Consequences to the organization for mishandling the data
- B. Consent terms including the purpose of data collection
- C. Contact information for reporting violations of consent
- D. Industry standards for data breach notification

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 120

While planning a security audit, an IS auditor is made aware of a security review carried out by external consultants. It is MOST important for the auditor to:

- A. re-perform the security review.

- B. accept the findings and conclusions of the consultants.
- C. review similar reports issued by the consultants.
- D. assess the objectivity and competence of the consultants.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 121

Which of the following is the BEST IS audit strategy?

- A. Perform audits based on impact and probability of error and failure.
- B. Cycle general control and application audits over a two-year period.
- C. Conduct general control audits annually and application audits in alternating years.
- D. Limit audits to new application system developments.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 122

Which of the following is MOST important for an IS auditor to review when evaluating the effectiveness of an organization's incident response process?

- A. Past incident response actions
- B. Incident response staff experience and qualifications
- C. Results from management testing of incident response procedures
- D. Incident response roles and responsibilities

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 123

Which of the following observations would an IS auditor consider the GREATEST risk when conducting an audit of a virtual server farm for potential software vulnerabilities?

- A. The hypervisor is updated quarterly.
- B. Guest operating systems are updated monthly.
- C. Antivirus software has been implemented on the guest operating system only.
- D. A variety of guest operating systems operate on one virtual server.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 124

An internal audit department recently established a quality assurance (QA) program. Which of the following activities is MOST important to include as part of the QA program requirements?

- A. Ongoing monitoring of the audit activities
- B. Analysis of user satisfaction reports from business lines.
- C. Feedback from internal audit staff
- D. Long-term internal audit resource planning

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 125

Which of the following is the BEST control to detect errors in an accounts payable system?

- A. Alignment of the process to business objectives
- B. Quality control review of new payments
- C. Management approval of payments
- D. Input validation

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 126

When auditing a quality assurance plan, an IS auditor should be MOST concerned if the:

- A. quality assurance function is separate from the programming function.
- B. SDLC is coupled with the quality assurance plan.

- C. quality assurance function is periodically reviewed by internal audit.
- D. scope of quality assurance activities is undefined.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 127

The PRIMARY reason for an IS auditor to use data analytics techniques is to reduce which type of audit risk?

- A. Technology risk
- B. Inherent risk
- C. Detection risk
- D. Control risk

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 128

An IS audit manager has been asked to perform a quality review on an audit that the same manager also supervised. Which of the following is the manager's BEST response to this situation?

- A. Notify the audit committee of the situation.
- B. Escalate the situation to senior audit leadership.
- C. Determine whether audit evidence supports audit conclusions.
- D. Discuss with the audit team to understand how conclusions were reached.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 129

While reviewing similar issues in an organization's help desk system, an IS auditor finds that they were analyzed independently and resolved differently. This situation MOST likely indicates a deficiency in:

- A. IT service level management.
- B. change management.
- C. configuration management.
- D. problem management.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 130

An auditor is creating an audit program where the objective is to establish the adequacy of personal data privacy controls in a payroll process. Which of the following is MOST important to include?

- A. Approval of data changes
- B. Audit logging of administrative user activity
- C. Segregation of duties controls
- D. User access provisioning

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 131

An IS auditor auditing the effectiveness of utilizing a hot site will MOST likely:

- A. review reciprocal agreements.
- B. review logical access controls.
- C. evaluate physical access controls.
- D. analyze system restoration procedures.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 132

An IS auditor has assessed a payroll service provider's security policy and finds significant topics are missing. Which of the following is the auditor's BEST course of action?

- A. Recommend the service provider update their policy.

- B. Notify the service provider of the discrepancies.
- C. Report the risk to internal management.
- D. Recommend replacement of the service provider.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 133

While reviewing a hot site, the IS auditor discovers that one type of hardware platform is not installed. The IS auditor should FIRST:

- A. recommend the purchase and installation of hardware at the hot site.
- B. report the finding immediately to senior IS management.
- C. determine the business impact of the absence of the hardware.
- D. establish the lead time for delivery of a new machine.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 134

An IS auditor is reviewing the upgrading of an operating system. Which of the following would be the GREATEST audit concern?

- A. The lack of release notes
- B. The lack of change control
- C. The lack of malware protection
- D. The lack of activity logging

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 135

An IS auditor has been asked to assess the security of a recently migrated database system that contains personal and financial data for a bank's customers. Which of the following controls is MOST important for the auditor to confirm it in place?

- A. The default configurations have been changed.
- B. All tables in the database are normalized.
- C. The service port used by the database server has been changed.
- D. The default administration account is used after changing the account password.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 136

Which of the following is the MOST important determining factor when establishing appropriate timeframes for follow-up activities related to audit findings?

- A. Peak activity periods for the business
- B. Remediation dates included in management responses
- C. Availability of IS audit resources
- D. Complexity of business processes identified in the audit

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 137

An IS auditor has obtained a large data set containing multiple fields and non-numeric data for analysis. Which of the following activities will MOST improve the quality of conclusions derived from the use of a data analytics tool for this audit?

- A. Data anonymization
- B. Data classification
- C. Data stratification
- D. Data preparation

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 138

Which of the following is the MOST important requirement for an IS auditor to evaluate when reviewing a transmission of personally identifiable information (PII) between two organizations?

- A. Completeness

- B. Timeliness
- C. Necessity
- D. Accuracy

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 139

An IS auditor reviewed the business case for a proposed investment to virtualize an organization's server infrastructure. Which of the following is MOST likely to be included among the benefits in the project proposal?

- A. Fewer operating system licenses
- B. Better efficiency of logical resources
- C. Reduced hardware footprint
- D. Less memory and storage space

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 140

Which of the following is the BEST way to facilitate proper follow-up for audit findings?

- A. Schedule a follow-up audit for two weeks after the initial audit was completed.
- B. Conduct a surprise audit to determine whether remediation is in progress.
- C. Conduct a follow-up audit when findings escalate to incidents.
- D. Schedule a follow-up audit based on remediation due dates.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 141

Which of the following would be the MOST efficient audit approach, given that a compliance-based approach was adopted in the previous year?

- A. Validate all applications using test data.
- B. Interview systems personnel to evaluate all automated controls.
- C. Evaluate the controls surrounding changes to programs.
- D. Perform a review of significant transactions posted within the system.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 142

An IS auditor will be testing accounts payable controls by performing data analytics on the entire population of transactions. Which of the following is MOST important for the auditor to confirm when sourcing the population data?

- A. There is no privacy information in the data.
- B. The data analysis tools have been recently updated.
- C. The data can be obtained in a timely manner.
- D. The data is taken directly from the system.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 143

Which of the following should the IS auditor use to BEST determine whether a project has met its business objectives?

- A. Earned-value analysis
- B. Completed project plan
- C. Issues log with resolutions
- D. Benefits realization document

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 144

An IS auditor is observing transaction processing and notes that a high-priority update job ran out of sequence. What is the MOST significant risk from this observation?

- A. Previous jobs may have failed.

- B. The job may not have run to completion.
- C. Daily schedules may not be accurate.
- D. The job competes with invalid data.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 145

During an audit of the organization's data privacy policy, the IS auditor identified that only some IT application databases have encryption in place. What should be the auditor's FIRST action?

- A. Assess the resources required to implement encryption to unencrypted databases.
- B. Review the most recent database penetration testing results.
- C. Determine whether compensating controls are in place.
- D. Review a comprehensive list of databases with the information they contain.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 146

Which of the following should be of GREATEST concern to an IS auditor reviewing actions taken during a forensic investigation?

- A. The investigation report does not indicate a conclusion.
- B. An image copy of the attacked system was not taken.
- C. The proper authorities were not notified.
- D. The handling procedures of the attacked system are not documented.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 147

An IS auditor evaluating a three-tier client/server architecture observes an issue with graphical user interface (GUI) tasks. Which layer should the auditor recommend the client address?

- A. Presentation layer
- B. Application layer
- C. Storage layer
- D. Transport layer

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 148

An IS auditor is assigned to review the development of a specific application. Which of the following would be the MOST significant step following the feasibility study?

- A. Attend project progress meetings to monitor timely implementation of the application.
- B. Assist users in the design of proper acceptance-testing procedures.
- C. Follow up with project sponsor for project's budgets and actual costs.
- D. Review functional design to determine that appropriate controls are planned.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 149

An IS audit report highlighting inadequate network internal controls is challenged because no serious incident has ever occurred. Which of the following actions performed during the audit would have BEST supported the findings?

- A. Compliance testing
- B. Threat risk assessment
- C. Penetration testing
- D. Vulnerability assessment

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 150

An IS auditor is performing a post-implementation review of a system deployed two years ago. Which of the following findings should be of MOST concern to the auditor?

- A. Maintenance costs were not included in the project lifecycle costs.
- B. Benefits as stated in the business case have not been realized.
- C. Workarounds due to remaining defects had to be used longer than anticipated.
- D. The system has undergone several change requests to further extend functionality.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 151

Which of the following should an IS auditor recommend as MOST critical to an effective performance improvement process for IT services?

- A. Progress on performance goals is regularly reported to the board.
- B. The performance goals are aligned with a commonly accepted framework.
- C. Root cause analysis of service issues is used to develop performance goals.
- D. Management accepts accountability for achieving performance goals.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 152

In reviewing the IT strategic plan, the IS auditor should consider whether it identifies the:

- A. major IT initiatives.
- B. links to operational tactical plans.
- C. allocation of IT staff
- D. project management methodologies used.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 153

During a review of system access, an IS auditor notes that an employee who has recently changed roles within the organization still has previous access rights. The auditor's NEXT step should be to:

- A. determine the reason why access rights have not been revoked.
- B. recommend a control to automatically update access rights.
- C. direct management to revoke current access rights.
- D. determine if access rights are in violation of software licenses.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 154

When engaging services from external auditors, which of the following should be established FIRST?

- A. Termination conditions agreements
- B. Nondisclosure agreements
- C. Service level agreements
- D. Operational level agreements

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 155

An IS auditor reviewing an incident management process identifies client information was lost due to ransomware attacks. Which of the following would MOST effectively minimize the impact of future occurrences?

- A. Change access to client data to read-only.
- B. Improve the ransomware awareness program.
- C. Back up client data more frequently.
- D. Monitor all client data changes.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 156

Which of the following is the PRIMARY benefit of implementing configuration management for IT?

- A. It helps audit in verifying IT conformance to business requirements.

- B. It establishes the dependency of application systems with various IT assets.
- C. It provides visibility to the overall function and technical attributes of IT assets.
- D. It helps automate change and release management processes in IT.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 157

The independence of an IS auditor auditing an application is maintained if the auditor's role is limited to:

- A. creating system specifications.
- B. defining user requirements.
- C. recommending system enhancements.
- D. designing access control rules.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 158

Which of the following is the PRIMARY reason for an IS auditor to use computer-assisted audit techniques (CAATs)?

- A. To efficiently test an entire population
- B. To perform direct testing of production data
- C. To conduct automated sampling for testing
- D. To enable quicker access to information

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 159

An IS auditor is planning to audit an organization's infrastructure for access, patching, and change management. Which of the following is the BEST way to prioritize the systems?

- A. Complexity of the environment
- B. Criticality of the system
- C. System hierarchy within the infrastructure
- D. System retirement plan

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 160

Which of the following would be the GREATEST concern to an IS auditor reviewing an IT outsourcing arrangement?

- A. Several IT personnel perform the same functions as the vendor.
- B. The contract does not include a renewal option.
- C. Development of KPIs that will be used was assigned to the vendor.
- D. Some penalties were waived during contract negotiations.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 161

When evaluating whether the expected benefits of a project have been achieved, it is MOST important for an IS auditor to review:

- A. post-implementation issues.
- B. quality assurance results.
- C. the project schedule.
- D. the business case.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 162

To BEST evaluate the effectiveness of a disaster recovery plan (DRP), the IS auditor should review the:

- A. test plan and results of past tests.
- B. plans and procedures in the business continuity plan (BCP).
- C. capacity of backup facilities.

D. hardware and software inventory.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 163

During an audit of a mission-critical system hosted in an outsourced data center, an IS auditor discovers that contracted routine maintenance for the alternate power generator was not performed. Which of the following should be the auditor's MAIN concern?

- A. Fraudulent behavior by the outsourcer charging for work not performed
- B. Failure of the alternate power generator during a power outage
- C. High repair costs if faulty generator parts are not detected in a timely manner
- D. Loss of warranty due to lack of system maintenance

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 164

An internal audit department recently established a quality assurance (QA) program as part of its overall audit program. Which of the following activities should be included as part of the QA program requirements?

- A. Reporting program results to the board
- B. Reviewing audit standards periodically
- C. Analyzing user satisfaction reports from business lines
- D. Conducting long-term planning for internal audit staffing

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 165

A previously agreed-upon recommendation was not implemented because the auditee no longer agrees with the original finding. What should be the IS auditor's FIRST course of action?

- A. exclude the finding in the follow-up audit report.
- B. escalate the disagreement to the audit committee.
- C. assess the reason for the disagreement.
- D. require implementation of the original recommendation.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 166

An IS auditor has observed gaps in the data available to the organization for detecting incidents. Which of the following would be the BEST recommendation to improve the organization's security incident response

capability?

- A. Document procedures for incident escalation.
- B. Document procedures for incident classification.
- C. Correlate security logs collected from multiple sources.
- D. Centralize alerts and security log information.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 167

When reviewing the effectiveness of data center operations, the IS auditor would FIRST establish that system performance:

- A. is monitored and reported against agreed service levels.
- B. reflects the expected usage levels established at implementation.
- C. meets the expected targets specified by the manufacturer.
- D. is within generally accepted reliability levels for that system.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 168

An organization has purchased a replacement mainframe computer to cope with the demands of increased business. Which of the following should be the PRIMARY concern of an IS auditor?

- A. The disaster recovery plan has been reviewed and updated.
- B. Application access controls are adequate.
- C. Appropriate tender evaluation processes have been followed.
- D. The procurement is within the planned budget for the year.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 169

An IS auditor discovers instances where software with the same license key is deployed to multiple workstations, in breach of the licensing agreement. Which of the following is the auditor's BEST recommendation?

- A. Evaluate the business case for funding of additional licenses.
- B. Require business owner approval before granting software access.
- C. Remove embedded keys from offending packages.
- D. Implement software licensing monitoring to manage duplications.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 170

The GREATEST benefit of risk-based auditing is that it:

- A. demonstrates compliance with regulatory requirements.
- B. enables alignment of resources to significant risk areas.
- C. allows an organization to identify and eliminate low-risk areas.
- D. identifies problem areas within an organization.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 171

Which of the following are BEST suited for continuous auditing?

- A. Manual transactions
- B. Irregular transactions
- C. Low-value transactions
- D. Real-time transactions

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 172

An organization's data retention policy states that all data will be backed up, retained for 10 years, and then destroyed. When conducting an audit of the long-term offsite backup program, an IS auditor should:

- A. verify that business owners review data before it is destroyed.
- B. verify that there is a process to ensure readability and restore capability.
- C. confirm that business interruption insurance coverage is in place.
- D. review data classification schemes for appropriate security levels.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 173

Which of the following is the MOST important for an IS auditor to do during an exit meeting with an auditee?

- A. Ensure that the facts presented in the report are correct.
- B. Specify implementation dates for the recommendations.
- C. Request input in determining corrective action.
- D. Communicate the recommendations to senior management.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 174

Which of the following should be of GREATEST concern to an IS auditor conducting an audit of incident response procedures?

- A. End users have not completed security awareness training.

- B. Senior management is not involved in the incident response process.
- C. There is no procedure in place to learn from previous security incidents.
- D. Critical incident response events are not recorded in a centralized repository.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 175

An IS auditor finds that confidential company data has been inadvertently leaked through social engineering. The MOST effective way to help prevent a recurrence of this issue is to implement:

- A. penalties to staff for security policy breaches.
- B. a third-party intrusion prevention solution.
- C. a security awareness program.
- D. data loss prevention (DLP) software.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 176

An organization is developing data classification standards and has asked internal audit for advice on aligning the standards with best practices. Internal audit would MOST likely recommend the standards should be:

- A. based on the results of an organization-wide risk assessment.
- B. based on the business requirements for confidentiality of the information.
- C. aligned with the organization's segregation of duties requirements.
- D. based on the business requirements for authentication of the information.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 177

Which of the following would an IS auditor consider to be the MOST significant risk associated with a project to reengineer a business process?

- A. The negative impact of change may not be documented.
- B. The project manager is inexperienced in information systems.
- C. Existing controls may be weakened or removed.
- D. Existing baseline processes may not be reported to management.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 178

A web organization is developed in-house by an organization. Which of the following would provide the BEST evidence to an IS auditor that the application is secure from external attack?

- A. Code review by a third party
- B. Web application firewall implementation
- C. Penetration test results
- D. Database application monitoring logs

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 179

Internal audit reports should be PRIMARILY written for and communicated to:

- A. audit management, as they are responsible for the quality of the audit.
- B. external auditors, as they provide an opinion on the financial statements.
- C. auditees, as they will eventually have to implement the recommendations.
- D. senior management, as they should be informed about the identified risks.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 180

Which of the following is MOST important for an IS auditor to verify when reviewing a critical business application that requires high availability?

- A. Algorithms are reviewed to resolve process inefficiencies.

- B. Users participate in offsite business continuity testing.
- C. There is no single point of failure.
- D. Service level agreement (SLAs) are monitored.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 181

Which procedure provides the GREATEST assurance that corrective action to an audit report has been taken?

- A. Performing subsequent audit tests to verify resolution of the deficiencies
- B. Inquiring about the current status of the recommendation
- C. Reporting to the audit committee or the board of directors concerning specific action taken or lack thereof
- D. Requesting a written management reply to the audit report, identifying corrective action for each deficiency

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 182

Which of the following should be done FIRST to effectively define the IT audit universe for an entity with multiple business lines?

- A. Identify aggregate residual IT risk for each business line.
- B. Obtain a complete listing of the entity's IT processes.
- C. Obtain a complete listing of assets fundamental to the entity's businesses.
- D. Identify key control objectives for each business line's core processes.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 183

An IS auditor determines that a business continuity plan has not been reviewed and approved by management. Which of the following is the MOST significant risk associated with this situation?

- A. Continuity planning may be subject to resource constraints.
- B. The plan may not be aligned with industry best practice.
- C. Critical business processes may not be addressed adequately.
- D. The plan has not been reviewed by risk management.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 184

After an external IS audit, which of the following should be IT management's MAIN consideration when determining the prioritization of follow-up activities?

- A. The amount of time since the initial audit was completed.
- B. The materiality of the reported findings
- C. The availability of the external auditors
- D. The scheduling of major changes in the control environment

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 185

Which of the following is MOST important when planning a network audit?

- A. Determination of IP range in use
- B. Isolation of rogue access points
- C. Identification of existing nodes
- D. Analysis of traffic content

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 186

Which of the following is the MOST effective way to identify anomalous transactions when performing a payroll fraud audit?

- A. Substantive testing of payroll files
- B. Data analytics on payroll data
- C. Observation of payment processing

D. Sample-based review of pay stubs

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 187

During an audit, which of the following would be MOST helpful in establishing a baseline for measuring data quality?

- A. Built-in data error prevention application controls
- B. Industry standard business definitions
- C. Input from customers
- D. Validation of rules by the business

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 188

IS audit is asked to explain how local area network (LAN) servers can contribute to a rapid dissemination of viruses. The IS auditor's BEST response is that:

- A. the server's software is the prime target and is the first to be infected.
- B. the server's operating system exchanges data with each station starting at every log-on.
- C. the server's file sharing function facilitates the distribution of files and applications.
- D. users of a given server have similar usage of applications and files.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 189

An organization allows employees to use personally owned mobile devices to access customers' personal information. An IS auditor's GREATEST concern should be whether:

- A. mobile devices are compatible with company infrastructure.
- B. devices have the capability to segregate business and personal data.
- C. mobile device security policies have been implemented.
- D. devices have adequate storage and backup capabilities.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 190

During a review of an application system, an IS auditor identifies automated controls designed to prevent the entry of duplicate transactions. What is the BEST way to verify that the controls work as designed?

- A. Implement periodic reconciliations.
- B. Review quality assurance (QA) test results.
- C. Use generalized audit software for seeking data corresponding to duplicate transactions.
- D. Enter duplicate transactions in a copy of the live system.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 191

A bank is selecting a server for its retail accounts application. To ensure that the server can handle a high volume of transactions with the required response times, which test should the IS auditor recommend?

- A. Regression
- B. Acceptance
- C. Benchmark
- D. Integration

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 192

During business process reengineering (BPR) of a bank's teller activities, an IS auditor should evaluate:

- A. the impact of changed business processes.
- B. the cost of new controls.
- C. BPR project plans.

D. continuous improvement and monitoring plans.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 193

During an audit of an organization's incident management process, an IS auditor learns that the security operations team includes detailed reports of recent attacks in its communications to employees. Which of the following is the GREATEST concern with this situation?

- A. Employees may fail to understand the severity of the threats.
- B. The reports may be too complex for a nontechnical audience.
- C. Employees may misuse the information in the reports.
- D. There is not a documented procedure to communicate the reports.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 194

A large insurance company is about to replace a major financial application. Which of the following is the IS auditor's PRIMARY focus when conducting the pre-implementation review?

- A. Procedure updates
- B. Migration of data
- C. System manuals
- D. Unit testing

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 195

An audit team has a completed schedule approved by the audit committee. After starting some of the scheduled audits, executive management asked the team to immediately audit an additional process. There are not enough resources available to add the additional audit to the schedule. Which of the following is the BEST course of action?

- A. Revise the scope of scheduled audits.
- B. Propose a revised audit schedule.
- C. Approve overtime work to ensure the audit is completed.
- D. Consider scheduling the audit for the next period.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 196

An internal audit has found that critical patches were not implemented within the timeline established by policy without a valid reason. Which of the following is the BEST course of action to address the audit findings?

- A. Monitor and notify IT staff of critical patches.
- B. Evaluate patch management training.
- C. Perform regular audits on the implementation of critical patches.
- D. Assess the patch management process.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 197

A recent audit has identified that security controls required by the organization's policies have not been implemented for a particular application. What should the information security manager do NEXT to address this issue?

- A. Deny access to the application until the issue is resolved.
- B. Discuss the issue with data custodians to determine the reason for the exception.
- C. Report the issue to senior management and request funding to fix the issue.
- D. Discuss the issue with data owners to determine the reason for the exception.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 198

During a vulnerability assessment, an IS auditor finds a high-risk vulnerability in a public-facing web server used to process online customer orders via credit card. The IS auditor should FIRST:

- A. notify management.
- B. redesign the customer order process.
- C. document the finding in the report.
- D. suspend credit card processing.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 199
Which of the following is the PRIMARY objective of the IS audit function?

- A. Perform reviews based on standards developed by professional organizations.
- B. Reports to management on the functioning of internal controls.
- C. Certify the accuracy of financial data.
- D. Facilitate extraction of computer-based data for substantive testing.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 200
Which of the following should be an IS auditor's FIRST activity when planning an audit?

- A. Gain an understanding of the area to be audited.
- B. Document specific questions in the audit program.
- C. Create a list of key controls to be reviewed.
- D. Identify proper resources for audit activities.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 201
An organization was recently notified by its regulatory body of significant discrepancies in its reporting data. A preliminary investigation revealed that the discrepancies were caused by problems with the organization's data quality. Management has directed the data quality team to enhance their program. The audit committee has asked internal audit to be advisors to the process. After the data quality team identifies the system data at fault, which of the following should internal audit recommend as the NEXT step in the process?

- A. Create business rules that validate data quality.
- B. Develop an improvement plan.
- C. Identify the root cause of data quality problems.
- D. Identify the source data owners.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 202
To select a sample for testing, which must include the 80 largest client balances and a random sample of the rest, the IS auditor should recommend:

- A. sorting the file with a utility.
- B. use of generalized audit software.
- C. applying attribute sampling using software.
- D. development of an integrated test facility (ITF).

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 203
A database administrator (DBA) extracts a user listing for an auditor as testing evidence. Which of the following will provide the GREATEST assurance that the user listing is reliable?

- A. Requesting a query that returns the count of the users.
- B. Requesting a copy of the query that generated the user listing
- C. Obtaining sign-off from the DBA to attest that the list is complete
- D. Witnessing the DBA running the query in-person

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 204
During an audit, it is discovered that several suppliers with standing orders have been deleted from the

supplier master file. Which of the following controls would have BEST prevented such an occurrence?

- A. Logical relationship check
- B. Existence check
- C. Table look-ups
- D. Referential integrity

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 205

An IS auditor discovered that a firewall has more services than needed. The IS auditor's FIRST recommendation should be to:

- A. ensure logging is turned on.
- B. deploy a network penetration team.
- C. review configurations.
- D. eliminate services except for HTTPS.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 206

An IS auditor finds that firewalls are outdated and not supported by vendors. Which of the following should be the auditor's NEXT course of action?

- A. Determine the value of the firewall.
- B. Report the security posture of the organization.
- C. Report the mitigating controls.
- D. Determine the risk of not replacing the firewall.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 207

Which of the following would be MOST important for an IS auditor to review during an audit of an automated continuous monitoring process being used by the finance department?

- A. Resiliency of the monitoring service
- B. Dual control and approvals embedded in processes
- C. Management sign-off of test documentation
- D. Configuration of the monitoring tool

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 208

Which of the following should be of GREATEST concern to an IS auditor reviewing the controls for a continuous software release process?

- A. Release documentation is not updated to reflect successful deployment.
- B. Test libraries have not been reviewed in over six months.
- C. Developers are able to approve their own releases.
- D. Testing documentation is not attached to production releases.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 209

While executing follow-up activities, an IS auditor is concerned that management has implemented corrective actions that are different from those originally discussed and agreed with the audit function. In order to resolve the situation, the IS auditor's BEST course of action would be to:

- A. determine whether the alternative controls sufficiently mitigate the risk and record the results.
- B. reject the alternative controls and re-prioritize the original issue as high risk.
- C. postpone follow-up activities and escalate the alternative controls to senior audit management.
- D. schedule another audit due to the implementation of alternative controls.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 210

Which of the following communication modes should be of GREATEST concern to an IS auditor evaluating end-user networking?

- A. System-to-system
- B. Peer-to-peer
- C. Host-to-host
- D. Client-to-server

Correct Answer: B
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 211

An IS auditor is reviewing an organization's sales and purchasing system due to ongoing data quality issues. An analysis of which of the following would provide the MOST useful information to determine the revenue loss?

- A. Correlation between the number of issues and average downtime
- B. Cost of implementing data validation controls within the system
- C. Comparison of the cost of data acquisition and loss in sales revenue
- D. Correlation between data errors and loss in value of transactions

Correct Answer: D
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 212

During a review of an insurance company's claims system, the IS auditor learns that claims for specific medical procedures are acceptable only from females. This is an example of a:

- A. key verification.
- B. completeness check.
- C. reasonableness check.
- D. logical relationship check.

Correct Answer: D
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 213

Which of the following should be of concern to an IS auditor performing a software audit on virtual machines?

- A. Software licensing does not support virtual machines.
- B. Software has been installed on virtual machines by privileged users.
- C. Multiple users can access critical applications.
- D. Applications have not been approved by the CFO.

Correct Answer: A
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 214

An IS auditor is evaluating the log management system for an organization with devices and systems in multiple geographic locations. Which of the following is MOST important for the auditor to verify?

- A. Log files are encrypted and digitally signed.
- B. Log files of the servers are synchronized.
- C. Log files are reviewed in multiple locations.
- D. Log files are concurrently updated.

Correct Answer: B
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 215

An IS auditor reviews change control tickets and finds an emergency change request where an IT manager approved the change, modified the code on the production platform, and resolved the ticket. Which of the following should be the auditor's GREATEST concern?

- A. There was no follow-up approval from the business.
- B. The change was made less than an hour after the request.
- C. There was no testing prior to making the change in production.
- D. The IT manager performed the change and resolved the ticket.

Correct Answer: D
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 216

During a help desk review, an IS auditor determines the call abandonment rate exceeds agreed-upon service levels. What conclusion can be drawn from this finding?

- A. There are insufficient telephone lines available to the help desk.
- B. There is insufficient staff to handle the help desk call volume.
- C. Help desk staff are unable to resolve a sufficient number of problems on the first call.
- D. Users are finding solutions from alternative sources.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 217

An IS auditor begins an assignment and identifies audit components for which the auditor is not qualified to assess. Which of the following is the BEST course of action?

- A. Notify audit management for a decision on how to proceed.
- B. Complete the audit and give full disclosure in the final audit report.
- C. Complete the work assignment to the best of the auditor's ability.
- D. Exclude the related tests from the audit plan and continue the assignment.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 218

When reviewing backup policies, an IS auditor MUST verify that backup intervals of critical systems do not exceed which of the following?

- A. Recovery point objective (RPO)
- B. Recovery time objective (RTO)
- C. Service level objective (SLO)
- D. Maximum acceptable outage (MAO)

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 219

Which of the following projects would be MOST important to review in an audit of an organization's financial statements?

- A. Resource optimization of the enterprise resource planning (ERP) system
- B. Security enhancements to the customer relationship database
- C. Automation of operational risk management processes
- D. Outsourcing of the payroll system to an external service provider

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 220

An internal IS auditor recommends that incoming accounts payable payment files be encrypted. Which type of control is the auditor recommending?

- A. Corrective
- B. Detective
- C. Preventive
- D. Directive

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 221

An IS auditor reviewing the use of encryption finds that the symmetric key is sent by an email message between the parties. Which of the following audit responses is correct in this situation?

- A. An audit finding is recorded, as the key should be asymmetric and therefore changed.
- B. No audit finding is recorded, as it is normal to distribute a key of this nature in this manner.
- C. No audit finding is recorded, as the key can only be used once.
- D. An audit finding is recorded, as the key should be distributed in a secure manner.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 222

Which of the following is the GREATEST risk resulting from conducting periodic reviews of IT over several years based on the same audit program?

- A. The amount of errors will increase because the routine work promotes inattentiveness.
- B. Detection risk is increased because auditees already know the audit program.
- C. Audit risk is increased because the programs might not be adapted to the organization's current situation.
- D. Staff turnover in the audit department will increase because fieldwork becomes less interesting.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 223
What is the FIRST step an auditor should take when beginning a follow-up audit?

- A. Review workpapers from the previous audit.
- B. Gather evidence of remediation to conduct tests of controls.
- C. Review previous findings and action plans.
- D. Meet with the auditee to discuss remediation progress.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 224
Following an IS audit, which of the following types of risk would be MOST critical to communicate to key stakeholders?

- A. Control
- B. Residual
- C. Audit
- D. Inherent

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 225
During an audit of information security procedures of a large retailer's online store, an IS auditor notes that operating system (OS) patches are automatically deployed upon release. Which of the following should be of GREATEST concern to the auditor?

- A. Patches are in conflict with current licensing agreements.
- B. Patches are pushed from the vendor increasing Internet traffic.
- C. Patches are not reflected in the configuration management database.
- D. Patches are not tested before installation on critical servers.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 226
Which of the following is the BEST way to address ongoing concerns with the quality and accuracy of internal audits?

- A. Engage an independent review of the audit function.
- B. Require peer reviews of audit workpapers.
- C. Implement performance management for IS auditors.
- D. Require IS audit management to lead exit meetings.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 227
An IS auditor finds that periodic reviews of read-only users for a reporting system are not being performed. Which of the following should be the IS auditor's NEXT course of action?

- A. Obtain a verbal confirmation from IT for this exemption.
- B. Review the list of end-users and evaluate for authorization.
- C. Verify management's approval for this exemption.
- D. Report this control process weakness to senior management.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 228
Which of the following activities would allow an IS auditor to maintain independence while facilitating a control self-assessment (CSA)?

- A. Developing the CSA questionnaire

- B. Developing the remediation plan
- C. Implementing the remediation plan
- D. Partially completing the CSA

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 229

What should an IS auditor do when informed that some recommendations cannot be implemented due to financial constraints?

- A. Document management's response in the working papers.
- B. Insist the recommendations be implemented.
- C. Agree to waive the recommendations.
- D. Suggest management identify cost-effective alternatives.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 230

Which of the following audit procedures would be MOST conclusive in evaluating the effectiveness of an e-commerce application system's edit routine?

- A. Interviews with knowledgeable users
- B. Use of test transactions
- C. Review of source code
- D. Review of program documentation

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 231

Which of the following would be an auditor's GREATEST concern when reviewing data inputs from spreadsheets into the core finance system?

- A. Undocumented code formats data and transmits directly to the database.
- B. There is not a complete inventory of spreadsheets, and file naming is inconsistent.
- C. Spreadsheets are accessible by all members of the finance department.
- D. The department data protection policy has not been reviewed or updated for two years.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 232

Which of the following should be an IS auditor's FIRST action when assessing the risk associated with unstructured data?

- A. Implement strong encryption for unstructured data.
- B. Implement user access controls to unstructured data.
- C. Identify repositories of unstructured data.
- D. Identify appropriate tools for data classification.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 233

Management has agreed to perform multiple remediation actions in response to an audit issue, including the implementation of a new control. Which of the following is the BEST time for an IS auditor to perform an audit follow-up of this issue?

- A. After management has completed the required actions
- B. When audit resources are available
- C. When management resources are available
- D. After the new control has been in place for one year

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 234

An IS audit reveals that an organization is not proactively addressing known vulnerabilities. Which of the following should the IS auditor recommend the organization do FIRST?

- A. Verify the disaster recovery plan (DRP) has been tested.
- B. Ensure the intrusion prevention system (IPS) is effective.

- C. Confirm the incident response team understands the issue.
- D. Assess the security risks to the business.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 235

An IS auditor concludes that a local area network's (LAN's) access security is satisfactory. In reviewing the work, the audit manager should:

- A. re-perform some steps of the audit to verify the quality of the work.
- B. verify that the elements of an agreed-upon audit plan have been addressed.
- C. verify user management's agreement with the findings.
- D. assess whether the auditor had the appropriate skills to perform the work.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 236

As part of an IS audit, the auditor notes the practices listed below. Which of the following would be a segregation of duties concern?

- A. Operators are degaussing magnetic tapes during night shifts.
- B. System programmers have logged access to operating system parameters.
- C. System programmers are performing the duties of operators.
- D. Operators are acting as tape librarians on alternate shifts.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 237

During an audit, the client learns that the IS auditor has recently completed a similar security review at a competitor. The client inquires about the competitor's audit results. What is the BEST way for the auditor to address this inquiry?

- A. Explain that it would be inappropriate to discuss the results of another audit client.
- B. Escalate the question to the audit manager for further action.
- C. Discuss the results of the audit omitting specifics related to names and products.
- D. Obtain permission from the competitor to use the audit results as examples for future clients.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 238

Which of the following is MOST important for an IS auditor to verify when reviewing an organization's information security practices following the adoption of a bring your own device (BYOD) program?

- A. Only applications approved by information security may be installed on devices.
- B. The expected benefits of adopting the BYOD program have been realized.
- C. Security policies have been updated to include BYOD.
- D. Remote wipe is enabled for devices allowed by BYOD.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 239

An IS auditor is asked to review a large organization's change management process. Which of the following practices presents the GREATEST risk?

- A. Emergency code changes are promoted without user acceptance testing.
- B. A system administrator performs code migration on planned downtime.
- C. Change management tickets do not contain specific documentation.
- D. Transaction data changes can be made by a senior developer.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 240

Which of the following BEST demonstrates to an IS auditor that an organization has implemented effective risk management processes?

- A. Critical business assets have additional controls.
- B. The risk register is reviewed periodically.

- C. A business impact analysis (BIA) has been completed.
- D. The inventory of IT assets includes asset classification.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 241

During an audit of a data center, an IS auditor's BEST way to gain an understanding of physical security controls is to:

- A. review the data center's physical security procedures.
- B. contact the alarm vendor and identify where alarms are installed in the data center.
- C. take a tour of the facility and identify physical security controls.
- D. obtain the engineering plans for the building and identify points of entry.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 242

An IS auditor finds that an organization's data loss prevention (DLP) system is configured to use vendor default settings to identify violations. The auditor's MAIN concern should be that:

- A. violations may not be categorized according to the organization's risk profile.
- B. violation reports may not be retained according to the organization's risk profile.
- C. violation reports may not be reviewed in a timely manner.
- D. a significant number of false positive violations may be reported.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 243

Which of the following IS audit recommendations would BEST help to ensure appropriate mitigation will occur on control weaknesses identified during an audit?

- A. Assign actions to responsible personnel and follow up.
- B. Report on progress to the audit committee.
- C. Perform a cost-benefit analysis on remediation strategy.
- D. Implement software to input the action points from the IS audit.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 244

During a database audit, an IS auditor noted frequent problems due to the growing size of the order tables. Which of the following is the BEST recommendation in this situation?

- A. Develop an archiving approach.
- B. Periodically delete completed orders.
- C. Build more table indices.
- D. Migrate to a different database management system.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 245

Which of the following procedures should an IS auditor complete FIRST when evaluating the adequacy of IT key performance indicators (KPIs)?

- A. Independently calculate the accuracy of the KPIs.
- B. Review KPIs that indicate poor IT performance.
- C. Validate the KPI thresholds.
- D. Determine whether the KPIs support IT objectives.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 246

During an audit of an organization's financial statements, an IS auditor finds that the IT general controls are deficient. What should the IS auditor recommend?

- A. Increase the compliance testing of the application controls.
- B. Place greater reliance on the application controls.
- C. Increase the substantive testing of the financial balances.

D. Place greater reliance on the framework of control.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 247

An internal review reveals an out-of-support human resources system. Which of the following is MOST important to determine when evaluating the associated risk?

- A. Frequency of outages associated with the out-of-support system
- B. The number of people accessing the out-of-support system
- C. Exposure of the out-of-support system outside of the network
- D. Timeline to replace the out-of-support system

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 248

Which of the following is MOST important for an IS auditor to consider when determining an appropriate sample size in situations where selecting the entire population is not feasible?

- A. Tolerable error
- B. Accessibility of the data
- C. Data integrity
- D. Responsiveness of the auditee

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 249

IT service engineers at a large organization are unable to effectively prioritize system-generated alerts from hundreds of applications running across multiple servers and databases. As a result, many alerts are often ignored, leading to major problems including downtime. Which of the following is the BEST IS audit recommendation to address this situation?

- A. Prioritize alerts from legacy applications that may require remote support from external vendors.
- B. Implement a threshold management system that prioritizes alerts over a certain age.
- C. Develop a classification scheme that prioritizes alerts according to potential business impact.
- D. Group alerts from related systems and immediately escalate to the application owner.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 250

An IS auditor finds that a mortgage origination team receives customer mortgage applications via a shared repository. Which of the following test procedures is the BEST way to assess whether there are adequate privacy controls over this process?

- A. Validate whether the encryption is compliant with the organization's requirements.
- B. Validate that data is entered accurately and timely.
- C. Validate whether documents are deleted according to data retention procedures.
- D. Validate whether complex passwords are required.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 251

An IS auditor observes an organization is performing data backup and restoration testing on an ad hoc basis without a defined process. What is the MOST likely result of a data disruption event?

- A. Increased loss impact
- B. Decreased data confidentiality
- C. Increased likelihood of future risk events
- D. Decreased data integrity

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 252

While reviewing the project plan for a new system prior to go-live, an IS auditor notes that the project team has not documented a fallback plan. Which of the following would be the BEST go-live approach in this situation?

- A. Parallel processing
- B. Immediate cutover
- C. Real-time replication
- D. Load balancing

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 253

Which of the following is MOST important for an IS auditor to determine when evaluating a database for privacy-related risks?

- A. Whether copies of production data are masked
- B. Whether the integrity of the data dictionary is maintained
- C. Whether data import and export procedures are approved
- D. Whether all database tables are normalized

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 254

Which of the following is MOST important for an IS auditor to consider when evaluating a Software as a Service (SaaS) arrangement?

- A. Total cost of ownership
- B. Frequency of software updates
- C. Physical security
- D. Software availability

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 255

Which of the following should be of GREATEST concern to an IS auditor when evaluating a new system's production readiness?

- A. A system defect was found during user acceptance testing.
- B. Functional design documentation is not complete.
- C. Functional requirements have not been met.
- D. Projected benefits have not been realized.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 256

Which of the following findings should be of GREATEST concern for an IS auditor when auditing the effectiveness of a phishing simulation test administered for staff members?

- A. Staff members were not notified about the test beforehand.
- B. Test results were not communicated to staff members.
- C. Staff members who failed the test did not receive follow-up education.
- D. Security awareness training was not provided prior to the test.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 257

During a review of an organization's network threat response process, the IS auditor noticed that the majority of alerts were closed without resolution. Management responded that those alerts were unworkable due to lack of actionable intelligence, and therefore the support team is allowed to close them. What is the BEST way for the auditor to address this situation?

- A. Further review closed unactioned alerts to identify mishandling of threats.
- B. Omit the finding from the report as this practice is in compliance with the current policy.
- C. Recommend that management enhance the policy and improve threat awareness training.
- D. Reopen unactioned alerts and report to the audit committee.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 258

An IS auditor would MOST likely recommend that IT management use a balanced scorecard to:

- A. ensure that IT staff meet performance requirements.
- B. train and educate IT staff.
- C. indicate whether the organization meets quality standards.
- D. assess IT functions and processes.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 259

Which of the following should an IS auditor recommend to reduce the likelihood of potential intruders using social engineering?

- A. Perform simulated attacks.
- B. Prohibit the use of social networking platforms.
- C. Implement an intrusion detection system (IDS).
- D. Deploy a security awareness program.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 260

An IS auditor notes that the anticipated benefits from an ongoing infrastructure project have changed due to recent organizational restructuring. Which of the following is the IS auditor's BEST recommendation?

- A. Review and reapprove the business case.
- B. Revise business goals and objectives.
- C. Conduct a new feasibility study.
- D. Review and update the business impact analysis (BIA).

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 261

When reviewing a newly implemented quality management system (QMS), which of the following should be the IS auditor's PRIMARY concern?

- A. The QMS benefit measures were not included in the business case.
- B. The QMS testing methodology is not clearly documented.
- C. The QMS post-implementation review (PIR) has not been finalized.
- D. The QMS is not mapped to some core business processes.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 262

What would be an IS auditor's GREATEST concern when using a test environment for an application audit?

- A. Test and production environments lack data encryption.
- B. Developers have access to the test environment.
- C. Retention period of test data has been exceeded.
- D. Test and production environments do not mirror each other.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 263

After the release of an application system, an IS auditor wants to verify that the system is providing value to the organization. The auditor's BEST course of action would be to:

- A. review the results of compliance testing.
- B. quantify improvements in client satisfaction.
- C. confirm that risk has declined since the application system release.
- D. perform a gap analysis against the benefits defined in the business case.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 264

What is an IS auditor's BEST recommendation for management if a network vulnerability assessment confirms that critical patches have not been applied since the last assessment?

- A. Implement a process to test and apply appropriate patches.
- B. Apply available patches and continue periodic monitoring.
- C. Configure servers to automatically apply available patches.
- D. Remove unpatched devices from the network.

Correct Answer: A
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 265

During a review of a production schedule, an IS auditor observes that a staff member is not complying with mandatory operational procedures. The auditor's NEXT step should be to:

- A. determine why the procedures were not followed.
- B. include the noncompliance in the audit report.
- C. note the noncompliance in the audit working papers.
- D. issue an audit memorandum identifying the noncompliance.

Correct Answer: A
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 266

Which of the following should an IS auditor be MOST concerned with when a system uses radio frequency identification (RFID)?

- A. Scalability
- B. Maintainability
- C. Nonrepudiation
- D. Privacy

Correct Answer: D
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 267

An IS auditor conducts a review of a third-party vendor's reporting of key performance indicators (KPIs). Which of the following findings should be of MOST concern to the auditor?

- A. Some KPIs are not documented.
- B. KPIs have never been updated.
- C. KPIs data is not being analyzed.
- D. KPIs are not clearly defined.

Correct Answer: D
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 268

An IS auditor notes that application of super-user activity was not recorded in system logs. What is the auditor's BEST course of action?

- A. Recommend a least-privilege access model.
- B. Investigate the reason for the lack of logging.
- C. Report the issue to the audit manager.
- D. Recommend activation of super-user activity logging.

Correct Answer: B
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 269

An IS auditor discovers a recurring software control process issue that severely impacts the efficiency of a critical business process. Which of the following is the BEST recommendation?

- A. Replace the malfunctioning system.
- B. Determine the compensating controls.
- C. Identify other impacted processes.
- D. Determine the root cause of the issue.

Correct Answer: D
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 270

An employee transfers from an organization's risk management department to become the lead IS auditor. While in the risk management department, the employee helped develop the key performance indicators (KPIs) now used by the organization. Which of the following would pose the GREATEST threat to the independence of this auditor?

- A. Evaluating the effectiveness of IT risk management processes
- B. Recommending controls to address the IT risks identified by KPIs
- C. Developing KPIs to measure the internal audit team
- D. Training the IT audit team on IT risk management processes

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 271

Following a security breach in which a hacker exploited a well-known vulnerability in the domain controller, an IS auditor has been asked to conduct a control assessment. The auditor's BEST course of action would be to determine if:

- A. the domain controller was classified for high availability.
- B. the network traffic was being monitored.
- C. the patches were updated.
- D. the logs were monitored.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 272

Which of the following should be of GREATEST concern to an IS auditor conducting an audit of an organization's backup processes?

- A. A written backup policy is not available.
- B. Backup failures are not resolved in a timely manner.
- C. The restoration process is slow due to connectivity issues.
- D. The service levels are not achieved.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 273

Performance monitoring tools report that servers are consistently above the recommended utilization capacity. Which of the following is the BEST recommendation of the IS auditor?

- A. Develop a capacity plan based on usage projections.
- B. Deploy load balancers.
- C. Monitor activity logs.
- D. Add servers until utilization is at target capacity.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 274

Which of the following would be MOST critical for an IS auditor to look for when evaluating fire precautions in a manned data center located in the upper floor of a multi-story building?

- A. Existence of handheld fire extinguishers in highly visible locations
- B. Documentation of regular inspections by the local fire department
- C. Adequacy of the HVAC system throughout the facility
- D. Documentation of tested emergency evacuation plans

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 275

Which of the following findings should be an IS auditor's GREATEST concern when reviewing an organization's purchase of new IT infrastructure hardware?

- A. The new infrastructure arrived with default system settings.
- B. The new infrastructure has residual risk within the organization's risk tolerance.
- C. The new infrastructure's hardening requirements are stronger than required by policy.
- D. The new infrastructure has compatibility issues with existing systems.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 276

The MOST effective method for an IS auditor to determine which controls are functioning in an operating

system is to:

- A. compare the current configuration to the corporate standard.
- B. consult with the systems programmer.
- C. consult with the vendor of the system.
- D. compare the current configuration to the default configuration.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 277

To test the integrity of the data in the accounts receivable master file, an IS auditor is particularly interested in reviewing customers with balances over \$400,000. The selection technique the IS auditor would use to obtain such a sample is called:

- A. random selection.
- B. systematic selection.
- C. discovery selection.
- D. stratification.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 278

During audit planning, an IS auditor walked through the design of controls related to a new data loss prevention (DLP) tool. It was noted that the tool will be configured to alert IT management when large files are sent outside of the organization via email. What type of control will be tested?

- A. Detective
- B. Corrective
- C. Directive
- D. Preventive

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 279

Which of the following should be of GREATEST concern to an IS auditor when auditing an organization's information security awareness program?

- A. Security awareness training is not included as part of the onboarding process for new hires.
- B. The number of security incidents logged by employees to the help desk has increased in the past year.
- C. Training quizzes are designed and run by a third-party company under a contract with the organization.
- D. Security awareness training is run via the organization's enterprise-wide e-learning portal.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 280

A legacy application is running on an operating system that is no longer supported by the vendor. If the organization continues to use the current application, which of the following should be the IS auditor's GREATEST concern?

- A. Potential exploitation of zero-day vulnerabilities in the system
- B. Inability to update the legacy application database
- C. Increased cost of maintaining the system
- D. Inability to use the operating system due to potential license issues

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 281

A 5-year audit plan provides for general audits every year and application audits on alternating years. To achieve higher efficiency, the IS audit manager would MOST likely:

- A. proceed with the plan and integrate all new applications.
- B. alternate between control self-assessment (CSA) and general audits every year.
- C. implement risk assessment criteria to determine audit priorities.
- D. have control self-assessments (CSAs) and formal audits of applications on alternating years.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 282

Which of the following would be an IS auditor's GREATEST concern when evaluating a cybersecurity incident response plan?

- A. The plan has not been recently tested.
- B. Roles and responsibilities are not detailed for each process.
- C. Stakeholder contact details are not up-to-date.
- D. The plan does not include incident response metrics.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 283

An organization has agreed to perform remediation related to high risk audit findings. The remediation process involves a complex reorganization of user roles as well as the implementation of several compensating controls that may not be completed within the next audit cycle. Which of the following is the BEST way for an IS auditor to follow up on the activities?

- A. Review the progress of remediation on a regular basis.
- B. Provide management with a remediation timeline and verify adherence.
- C. Continue to audit the failed controls according to the audit schedule.
- D. Schedule a review of the controls after the projected remediation date.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 284

The IS auditor's PRIMARY role in control self-assessment (CSA) is to:

- A. evaluate the controls.
- B. facilitate the process.
- C. identify weaknesses.
- D. draw up an action plan.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 285

Which of the following is an IS auditor's BEST course of action upon learning that preventive controls have been replaced with detective and corrective controls?

- A. Report the issue to management as the risk level has increased.
- B. Recommend the implementation of preventive controls in addition to the other controls.
- C. Verify the revised controls enhance the efficiency of related business processes.
- D. Evaluate whether new controls manage the risk at an acceptable level.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 286

Which of the following should the IS auditor do FIRST to ensure data transfer integrity for Internet of Things (IoT) devices?

- A. Verify access control lists to the database where collected data is stored.
- B. Confirm that acceptable limits of data bandwidth are defined for each device.
- C. Ensure that message queue telemetry transport (MQTT) is used.
- D. Determine how devices are connected to the local network.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 287

An IS auditor finds that corporate mobile devices used by employees have varying levels of password settings. Which of the following would be the BEST recommendation?

- A. Update the acceptable use policy for mobile devices.
- B. Notify employees to set passwords to a specified length.
- C. Encrypt data between corporate gateway and devices.
- D. Apply a security policy to the mobile devices.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 288

When planning an application audit, it is MOST important to evaluate risk factors by interviewing:

- A. process owners.
- B. application owners.
- C. IT management.
- D. application users.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 289
The scheduling of audit follow-ups should be based PRIMARILY on:

- A. costs and audit efforts involved.
- B. auditee and auditor time commitments.
- C. the risk and exposure involved.
- D. control and detection processes.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 290
A vendor service level agreement (SLA) requires backups to be physically secured. An IS audit of the backup system revealed a number of the backup media were missing. Which of the following should be the auditor's NEXT step?

- A. Recommend a review of the vendor's contract.
- B. Recommend identification of the data stored on the missing media.
- C. Notify executive management.
- D. Include the missing backup media finding in the audit report.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 291
An internal audit department recently established a quality assurance (QA) program as part of its overall audit program. Which of the following activities is MOST important to include as part of the QA program requirements?

- A. Implementing corrective action plans.
- B. Reviewing audit standards periodically
- C. Analyzing user satisfaction reports from business lines
- D. Creating a long-term plan for internal audit staffing

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 292
Which of the following would be of MOST concern for an IS auditor evaluating the design of an organization's incident management processes?

- A. Metrics are not reported to senior management.
- B. Service management standards are not followed.
- C. Expected time to resolve incidents is not specified.
- D. Prioritization criteria are not defined.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 293
During a review of an organization's IT incident management practices, the IS auditor finds the quality of incident resolution documentation is poor. Which of the following is the BEST recommendation to help address this issue?

- A. Have service desk staff create documentation by choosing from pre-selected answers in the service management tool.
- B. Require service desk staff to open incident tickets only when they have sufficient information.
- C. Revise incident resolution procedures and provide training for service desk staff on the applicable updates.
- D. Require peer review of resolution documentation followed by service desk management sign off.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 294
What is an IS auditor's BEST course of action when provided with a status update indicating audit recommendations related to segregation of duties for financial staff have been implemented?

- A. Verify sufficient segregation of duties controls are in place.
- B. Request documentation of the segregation of duties policy and procedures.
- C. Note the department's response in the audit workpapers and records.
- D. Confirm with the business that the recommendations are implemented.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 295

When reviewing capacity monitoring, an IS auditor notices several incidents where storage capacity limits were reached, while the average utilization was below 30%. Which of the following would the IS auditor MOST likely identify as the root cause?

- A. The IT response to the alerts was too slow.
- B. The amount of data produced was unacceptable for operations.
- C. The storage space should have been enlarged in time.
- D. The dynamics of the utilization were not properly taken into account.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 296

An IS auditor is reviewing the process followed in identifying and prioritizing the critical business processes. This process is part of the:

- A. balanced scorecard.
- B. business impact analysis (BIA).
- C. operations component of the business continuity plan (BCP).
- D. enterprise risk management plan.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 297

When assessing a business case as part of a post-implementation review, the IS auditor must ensure that the:

- A. feasibility of alternative project approaches has been assessed.
- B. business case has not been amended since project approval.
- C. quality assurance measures have been applied throughout the project.
- D. amendments to the business case have been approved.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 298

While auditing an IT department's cloud service provider, the IS auditor found that privileged access monitoring is not being performed as required by the contract. The provider disagrees with this issue and notes that compensating controls are in place. The IS auditor's NEXT course of action should be to:

- A. test compensating controls as part of the audit.
- B. define a remediation plan.
- C. review privileged access logs.
- D. recommend revising the service level agreement (SLA).

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 299

Which of the following should be of GREATEST concern to an IS auditor reviewing an organization's information security program?

- A. The program was not formally signed off by the sponsor.
- B. Key performance indicators (KPIs) are not established.
- C. Not all IT staff are aware of the program.
- D. The program was last updated five years ago.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 300

During an incident management audit, an IS auditor finds that several similar incidents were logged during the audit period. Which of the following is the auditor's MOST important course of action?

- A. Document the finding and present it to management.
- B. Determine if a root cause analysis was conducted.
- C. Validate whether all incidents have been actioned.
- D. Confirm the resolution time of the incidents.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 301

Which of the following responsibilities of an organization's quality assurance function should raise concern for an IS auditor?

- A. Ensuring the test work supports observations
- B. Ensuring standards are adhered to within the development process
- C. Implementing solutions to correct defects
- D. Updating development methodology

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 302

Which of the following is the MOST appropriate document for granting authority to an external IS auditor in an audit engagement with a client organization?

- A. Approved statement of work
- B. Formally approved audit charter
- C. An internal memo to all concerned parties
- D. Request for proposal for audit services

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 303

Which of the following is MOST important for an IS auditor to evaluate when determining the effectiveness of an information security program?

- A. Percentage of users aware of the objectives of the security program
- B. Percentage of policy exceptions that were approved with justification
- C. Percentage of desired control objectives achieved
- D. Percentage of reported security incidents

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 304

When auditing an organization's software acquisition process, the BEST way for an IS auditor to understand the software benefits to the organization would be to review the:

- A. request for proposal (RFP).
- B. feasibility study.
- C. alignment with IT strategy.
- D. business case.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 305

Which of the following should be the GREATEST concern to an IS auditor evaluating an organization's policies?

- A. Policies are not formally approved by the management.
- B. Policies are not formally acknowledged and signed by employees.
- C. Policies do not provide adequate protection to the organization.
- D. Policies are not reviewed and updated frequently.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 306

Which of the following is the BEST source of information for an IS auditor when planning an audit of a business application's controls?

- A. User documentation

- B. Change control procedures
- C. Access control lists
- D. Process flow diagrams

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 307

An IS auditor notes that a loan servicing group retains customer personally identifiable information (PII) on a shared drive. Which of the following is MOST important to ensure compliance with privacy principles?

- A. Backups are performed in accordance with organizational policy.
- B. Access to the shared drive must be approved by the manager of the group.
- C. The data is maintained in accordance with the business's retention policy.
- D. All key customer data elements are captured on the shared drive.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 308

An IS auditor is evaluating the access controls at a multinational company with a shared network infrastructure. Which of the following is MOST important?

- A. Simplicity of end-to-end communication paths
- B. Remote network administration
- C. Common security policies
- D. Logging of network information at user level

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 309

Which of the following is the MOST significant risk an IS auditor should consider when reviewing a credit card company's application system?

- A. Data privacy
- B. Processing times
- C. System availability
- D. Credit ratings

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 310

Which of the following should be an IS auditor's PRIMARY concern when evaluating an organization's information security policies, procedures, and controls for third-party vendors?

- A. The third-party vendors have their own information security requirements.
- B. The organization is still responsible for protecting the data.
- C. Noncompliance is easily detected.
- D. The same procedures and controls are used for all third-party vendors.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 311

During a follow-up audit, an IS auditor finds that some critical recommendations have not been addressed as management has decided to accept the risk. Which of the following is the IS auditor's BEST course of action?

- A. Adjust the annual risk assessment accordingly.
- B. Require the auditee to address the recommendations in full.
- C. Evaluate senior management's acceptance of the risk.
- D. Update the audit program based on management's acceptance of risk.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 312

As part of a follow-up of a previous year's audit, an IS auditor has increased the expected error rate for a sample. What is the impact?

- A. degree of assurance increases.

- B. standard deviation decreases.
- C. sampling risk decreases.
- D. required sample size increases.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 313

During a vendor management database audit, an IS auditor identifies multiple instances of duplicate vendor records. In order to prevent recurrence of the same issue, which of the following is the IS auditor's BEST recommendation to management?

- A. Perform system verification checks for unique data values on key fields.
- B. Request senior management approval of all new vendor details.
- C. Run system reports of full vendor listings periodically to identify duplication.
- D. Build a segregation of duties control into the vendor creation process.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 314

During the implementation of a new system, an IS auditor must assess whether certain automated calculations comply with the regulatory requirements. Which of the following is the BEST way to obtain this assurance?

- A. Inspect user acceptance test (UAT) results.
- B. Re-perform the calculation with audit software.
- C. Review sign-off documentation.
- D. Review the source code related to the calculation.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 315

An IS auditor has been asked to review a recently implemented quality management system (QMS). Which of the following should be the auditor's PRIMARY focus?

- A. Training materials prepared for coaching employees
- B. Processes to measure the performance of business critical transactions
- C. Documentation standard of the implemented QMS system
- D. Stability of the implemented QMS system over a period of time

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 316

Which of the following should be the PRIMARY concern of an IS auditor during a review of an external IT service level agreement (SLA) for computer operations?

- A. No employee succession plan
- B. Changes in services are not tracked
- C. Lack of software escrow provisions
- D. Vendor has exclusive control of IT resources

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 317

An IS auditor finds that one employee has unauthorized access to confidential data. The IS auditor's BEST

recommendation should be to:

- A. reclassify the data to a lower level of confidentiality.
- B. recommend corrective actions to be taken by the security administrator.
- C. implement a strong password schema for users.
- D. require the business owner to conduct regular access reviews.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 318

An IS auditor is reviewing an organization's primary router access control list. Which of the following should result in a finding?

- A. The network security group can change network address translation (NAT).
- B. There are conflicting permit and deny rules for the IT group.
- C. There is only one rule per group with access privileges.
- D. Individual permissions are overriding group permissions.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 319
Which of the following BEST describes an audit risk?

- A. The financial report may contain undetected material errors.
- B. The company is being sued for false accusations.
- C. Key employees have not taken vacation for 2 years.
- D. Employees have been misappropriating funds.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 320
An IS auditor notes that several of a client's servers are vulnerable to attack due to open unused ports and protocols. The auditor recommends management implement minimum security requirements. Which type of control has been recommended?

- A. Preventive
- B. Corrective
- C. Directive
- D. Compensating

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 321
Which of the following is the PRIMARY reason for an IS auditor to map out the narrative of a business process?

- A. To verify the business process is as described in the engagement letter
- B. To identify the resources required to perform the audit
- C. To ensure alignment with organizational objectives
- D. To gain insight into potential risks

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 322
Which of the following is the BEST way for an IS auditor to assess the effectiveness of backup procedures?

- A. Review the backup schedule.
- B. Evaluate the latest data restore.
- C. Inspect backup logs.
- D. Interview the data owner.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 323
An IS auditor is auditing the infrastructure of an organization that hosts critical applications withing a virtual environment. Which of the following is MOST important for the auditor to focus on?

- A. The ability to copy and move virtual machines in real time
- B. The controls in place to prevent compromise of the host
- C. Issues arising from system management of a virtual infrastructure
- D. Qualifications of employees managing the applications

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 324
When reviewing a database supported by a third-party service provider, an IS auditor found minor control deficiencies. The auditor should FIRST discuss recommendations with the:

- A. service provider support team manager
- B. organization's service level manager
- C. organization's chief information officer (CIO)
- D. service provider contract liaison

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 325

Following an IT audit, management has decided to accept the risk highlighted in the audit report. Which of the following would provide the MOST assurance to the IS auditor that management is adequately balancing the needs of the business with the need to manage risk?

- A. Established criteria exist for accepting and approving risk.
- B. Identified risk is reported into the organization's risk committee.
- C. Potential impact and likelihood is adequately documented.
- D. A communication plan exists for informing parties impacted by the risk.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 326

An IS auditor is performing a routine procedure to test for the possible existence of fraudulent transactions. Given there is no reason to suspect the existence of fraudulent transactions, which of the following data analytics techniques should be employed?

- A. Association analysis
- B. Classification analysis
- C. Anomaly detection analysis
- D. Regression analysis

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 327

Which of the following is an IS auditor's BEST recommendation for mitigating risk associated with rapid expansion of hosts within a virtual environment?

- A. Limit access to the hypervisor operating system (OS) and administration console
- B. Ensure quick access to updated images of a guest operating system for fast recovery
- C. Consider using a third-party service provider to share the virtual machine (VM) risk
- D. Implement policies and processes to control virtual machine (VM) lifecycle management

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 328

Which of the following is the MOST effective way for an IS auditor to evaluate the creation and deletion of administrative accounts in a virtual environment?

- A. Review password management procedures.
- B. Review accounts to determine access requirements.
- C. Review resource management for capacity performance.
- D. Review account provisioning and deprovisioning procedures.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 329

What should an IS auditor review FIRST when assessing the results of a recent penetration test to identify potential vulnerabilities?

- A. Skill level of the network support staff
- B. Parameters of the test
- C. Number of critical issues found
- D. Incident response process

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 330

While following up on a prior audit report, an IS auditor determines that a number of recommendations to address critical findings have not been implemented as agreed. What is the BEST course of action for the auditor?

- A. Reclassify the risk ratings of the original findings.
- B. Propose revised implementation timelines.
- C. Escalate to the appropriate level of management.
- D. Revise the scope of the follow-up audit

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 331

Which of the following would be of GREATEST concern to an IS auditor when auditing a small organization's purchasing department?

- A. The organization lacks a purchasing officer with experience in purchasing activities.
- B. Purchases can be approved after expenses have already been incurred.
- C. Some members of the department can request and approve payments for purchase requests.
- D. Purchasing procedures and processes have not been updated during the past two years.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 332

Which of the following audit procedures would BEST assist an IS auditor in determining the effectiveness of a business continuity plan (BCP)?

- A. Performing an assessment of BCP test documentation
- B. Participating in BCP meetings held with user department managers
- C. Performing a maturity assessment of BCP methodology against industry standards
- D. Observing tests of the BCP performed at the alternate processing site

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 333

After discussing findings with an auditee, an IS auditor is required to obtain approval of the report from the CEO before issuing it to the audit committee. This requirement PRIMARILY affects the IS auditor's:

- A. judgment
- B. effectiveness
- C. independence
- D. integrity

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 334

An organization wants to classify database tables according to its data classification scheme. From an IS auditor's perspective, the tables should be classified based on the:

- A. number of end users with access to the table
- B. frequency of updates to the table
- C. descriptions of column names in the table
- D. specific functional contents of each single table

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 335

Which of the following should be an IS auditor's GREATEST consideration when scheduling follow-up activities for agreed-upon management responses to remediate audit observations?

- A. Business interruption due to remediation
- B. IT budgeting constraints
- C. Risk rating of original findings
- D. Availability of responsible IT personnel

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 336

Which of the following is MOST important for an IS auditor to consider when auditing a vulnerability scanning software solution?

- A. The scanning software was purchased from an approved vendor.
- B. The scanning software was approved for release into production.
- C. The scanning software covers critical systems.
- D. The scanning software is cost-effective.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 337

An IS auditor attempts to sample for variables in a population of items with wide differences in values but determines that an unreasonably large number of sample items must be selected to produce the desired confidence level. In this situation, which of the following is the BEST audit decision?

- A. Allow more time and test the required sample
- B. Select a judgmental sample
- C. Select a stratified sample
- D. Lower the desired confidence level

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 338

A vulnerability in which of the following virtual systems should be of GREATEST concern to an IS auditor?

- A. The virtual machine management server
- B. The virtual application server
- C. The virtual antivirus server
- D. The virtual file server

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 339

What is an IS auditor's BEST course of action if informed by a business unit's representatives that they are too busy to cooperate with a scheduled audit?

- A. Reschedule the audit for a time more convenient to the business unit.
- B. Begin the audit regardless and insist on cooperation from the business unit.
- C. Notify the audit committee immediately and request they direct the audit begin on schedule.
- D. Notify the chief audit executive who can negotiate with the head of the business unit.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 340

An IS auditor wants to determine who has oversight of staff performing a specific task and is referencing the organization's RACI chart. Which of the following roles within the chart would provide this information?

- A. informed
- B. Accountable
- C. Consulted
- D. Responsible

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 341

Total billing amounts on invoices are automatically transferred to an organization's account ledger weekly. During an IS audit, the auditor discovers that one week's billing is missing from the ledger. Which of the

following areas should the auditor examine FIRST?

- A. Annual reconciliations
- B. Change management
- C. Batch processing controls
- D. Module access rights

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 342

Which of the following should an IS auditor review FIRST when evaluating incident management procedures?

- A. Command center monitoring
- B. Root cause analysis steps
- C. Prioritization criteria
- D. Peer review requirements

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 343

Which of the following is MOST important for an IS auditor to understand when planning an IS audit?

- A. Inherent risk of auditable areas
- B. Management focus on particular operations
- C. Number of high-risk auditable processes
- D. Availability of IS audit resources

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 344

An IS auditor finds ad hoc vulnerability scanning is in place with no clear alignment to the organization's wider security threat and vulnerability management program. Which of the following would BEST enable the organization to work toward improvement in this area?

- A. Outsourcing the threat and vulnerability management function to a third party
- B. Implementing security logging to enhance threat and vulnerability management
- C. Using a capability maturity model to identify a path to an optimized program
- D. Maintaining a catalog of vulnerabilities that may impact mission-critical systems

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 345

Which of the following observations should be of concern to an IS auditor in the fieldwork stage of a procurement audit?

- A. Requisitions are being processed by the finance team.
- B. The purchase requester receives notifications of goods delivery.
- C. Purchase commitments are made prior to requisitions being approved.
- D. Requisitions are being facilitated by a third-party procurement service.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 346

An audit of a database management system found the audit log was not restarted following maintenance. Which of the following is the GREATEST concern to the IS auditor?

- A. Changes by the database administrators will not be logged.
- B. The database optimization will be compromised.
- C. The database triggers and pointers will not be optimized.
- D. Changes by application users will not be logged.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 347

An IS auditor is reviewing an organization's method to transport sensitive data between offices. Which of the following would cause the auditor MOST concern?

- A. The method relies exclusively on the use of digital signatures.
- B. The method relies exclusively on the use of asymmetric encryption algorithms.
- C. The method relies exclusively on the use of public key infrastructure.
- D. The method relies exclusively on the use of symmetric encryption algorithms.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 348

During an integrated audit at a retail bank, an IS auditor is evaluating whether monthly service fees are appropriately charged for business accounts and waived for individual consumer accounts. Which of the following test approaches would utilize data analytics to facilitate the testing?

- A. Attempt to charge a monthly service fee to an individual consumer account.
- B. Evaluate whether user acceptance testing plans were designed and executed appropriately.
- C. Review customer accounts over the last year to determine whether appropriate charges were applied.
- D. Compare the system configuration settings with the business requirements document.

Correct Answer: C
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 349

An organization migrated most of its physical servers to virtual ones in its own data center. Which of the following should be of GREATEST concern to an IS auditor reviewing the virtual environment?

- A. Hypervisor access control lists are outdated.
- B. The configuration management database (CMDB) does not include all virtual machines.
- C. Hypervisors have not been updated with the most recent patches.
- D. Virtual machine deployments are done without following an approved template.

Correct Answer: D
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 350

An audit group is conducting a risk assessment as part of a risk-based audit strategy. To help ensure the risk assessment results are relevant to the organization, it is MOST important to:

- A. understand the organization's objectives and risk appetite.
- B. include operational departments and processes.
- C. determine both the inherent risk and detection risk.
- D. understand the organization's controls.

Correct Answer: A
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 351

Which of the following auditing techniques would be used to detect the validity of a credit card transaction based on time, location, and date of purchase?

- A. Benford's analysis
- B. Gap analysis
- C. Stratified sampling
- D. Data mining

Correct Answer: A
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 352

Which of the following activities should an IS auditor perform FIRST during an external network security assessment?

- A. Exploitation
- B. Enumeration
- C. Vulnerability scanning
- D. Reconnaissance

Correct Answer: B
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 353

An IS auditor observed that most users do not comply with physical access controls. The business manager has explained that the control design is inefficient. What is the auditor's BEST course of action?

- A. Recommend changing the access control process to increase efficiency.
- B. Identify the impact of control failure and report the finding with a risk rating.
- C. Redesign and retest the physical access control.
- D. Work with management to design and implement a better control.

Correct Answer: B
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 354

During a follow-up audit for a finding related to change management, an IS auditor notes that one of the changes sampled was an emergency change, which follows a different process. Which of the following is the auditor's BEST course of action?

- A. Mark the sample as not applicable in the workpaper and move on to testing the next sample.
- B. Select a replacement change for testing.
- C. Obtain evidence that the change was approved.
- D. Note the sample as a deviation and leave the finding open in the audit tracking log.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 355

In a small organization, an IS auditor finds that security administration and system analysis functions are performed by the same employee. Which of the following is the MOST significant finding?

- A. The security policy has not been updated to reflect the situation.
- B. The employee's formal job description has not been updated.
- C. The employee has not signed the security policy.
- D. The employee's activities are not independently reviewed.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 356

The PRIMARY purpose of an internal audit department's quality assurance improvement program is to evaluate which of the following?

- A. The adequacy and qualifications of internal audit personnel
- B. The effectiveness of the internal audit function
- C. The efficiency of internal audit processes
- D. The accuracy of prior-year internal audit results

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 357

To BEST determine if a project is successfully addressing business requirements while managing the associated risk, which of the following should an IS auditor expect to find at each significant milestone?

- A. Comprehensive end user acceptance testing
- B. Formal acceptance by appropriate stakeholders
- C. A revised business impact and risk analysis
- D. Post-implementation review with affected parties

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 358

An IS auditor has performed an agreed-upon procedures engagement for the organization's IT steering committee. Which of the following would be the MOST important element to include in the report?

- A. Complementary user entity controls
- B. Management's representation on the effectiveness of controls
- C. Statement that the engagement followed standards
- D. An opinion on the effectiveness of controls

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 359

An IS auditor notes that several users have not logged into an application for more than one year. Which of the following would be the BEST audit recommendation?

- A. Periodically review the information security policy.
- B. Update the termination procedures.
- C. Periodically review user access.
- D. Delete the affected users' IDs.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 360

A security review focused on data loss prevention (DLP) revealed the organization has no visibility to data stored in the cloud. What is the IS auditor's BEST recommendation to address this issue?

- A. Implement a file system scanner to discover data stored in the cloud.
- B. Utilize a DLP tool on desktops to monitor user activities.
- C. Employ a cloud access security broker (CASB).
- D. Enhance the firewall at the network perimeter.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 361

The BEST way for an IS auditor to determine which business processes are currently outsourced to a specific service provider is to review the:

- A. enterprise architecture (EA) diagram.
- B. service provider's contract.
- C. vendor management policy.
- D. request for proposal (RFP) responses.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 362

Prior to the migration of acquired software into production, it is MOST important that the IS auditor review the:

- A. user acceptance test report.
- B. vendor testing report.
- C. system documentation.
- D. source code escrow agreement.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 363

When auditing the security architecture of an e-commerce environment, an IS auditor should FIRST review the:

- A. configuration of the firewall
- B. alternate firewall arrangements
- C. location of the firewall within the network
- D. criteria used for selecting the firewall

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 364

An IS auditor reviewing a recently implemented virtual environment notices discrepancies among similar machine setups. Which of the following should the auditor recommend to minimize configuration risks?

- A. Implement network best practice recommendations
- B. Perform architectural vulnerability analysis to compare current system attributes to a reference
- C. Perform hypervisor software updates with available patches to minimize security weakness
- D. Implement templates to manage rapid deployment of virtual machines

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 365

An organization has selected a web-based solution to reduce transaction costs and improve productivity. Before implementation, an IS auditor should ensure that the organization has:

- A. performed a vulnerability assessment.
- B. implemented electronic data interchange.
- C. validated the solution against the current IT infrastructure.
- D. addressed the level of risk exposure.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 366

An organization with high availability resource requirements is selecting a provider for cloud computing. Which of the following would cause the GREATEST concern to an IS auditor? The provider:

- A. is not internationally certified for high availability.
- B. does not store backup media offsite.
- C. deploys patches automatically without testing.
- D. hosts systems for the organization's competitor.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 367
Which of the following BEST enables an audit department to improve the quality of work performed by its auditors?

- A. Implementing global quality standards
- B. Funding additional resources for audit work
- C. Using audit-related data analytics tools
- D. Implementing peer review of audit work

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 368
An IS auditor discovers that management has created a system interface to receive financial data and store it in a data warehouse. Which of the following provides the BEST assurance that data in the data warehouse is accurate?

- A. Established risk management processes
- B. A documented change management process
- C. Management access reviews
- D. Management reconciliations

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 369
An IS auditor performs a follow-up audit and learns the approach taken by the auditee to fix the findings differs from the agreed-upon approach confirmed during the last audit. Which of the following should be the auditor's NEXT course of action?

- A. Inform senior management of the change in approach.
- B. Conduct a risk analysis incorporating the change.
- C. Report results of the follow-up to the audit committee.
- D. Evaluate the appropriateness of the remedial action taken.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 370
An IS auditor is using data analytics for an accounts payable audit. Which of the following potential risk scenarios will MOST likely be identified using this approach?

- A. Rogue or shadow vendors
- B. Payments made to the wrong vendor
- C. Consecutive invoice numbers paid
- D. Duplicate payments made for a vendor

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 371
An IS auditor is evaluating the risk associated with moving from one database management system (DBMS) to another. Which of the following would be MOST helpful to ensure the integrity of the system throughout the change?

- A. Preserving the same data structure
- B. Preserving the same data classifications
- C. Preserving the same data interfaces
- D. Preserving the same data inputs

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 372
An IS auditor is performing a follow-up audit and notes that some critical deficiencies have not been addressed. The auditor's BEST course of action is to:

- A. assess the impact of not addressing deficiencies.
- B. document management's reasons for not addressing deficiencies.
- C. postpone the audit until the deficiencies are addressed.
- D. provide new recommendations.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 373
Which of the following is MOST important for an IS auditor to focus on when evaluating the quality control processes for software deliverables?

- A. The process to identify and manage defects
- B. The process to check adherence to technical specifications
- C. The process to produce quality control reports
- D. The process to peer review and test the software

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 374
An IS auditor is performing a follow-up audit for findings identified in an organization's user provisioning process. Which of the following is the MOST appropriate population to sample from when testing for remediation?

- A. All users who have followed user provisioning processes provided by management
- B. All users provisioned after the finding was originally identified
- C. All users provisioned after management resolved the audit issue
- D. All users provisioned after the final audit report was issued

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 375
An IS auditor is reviewing a sample of production incidents and notes that root cause analysis is not being performed. Which of the following is the GREATEST risk associated with this finding?

- A. Future incidents may not be resolved in a timely manner.
- B. Future incidents may be prioritized inappropriately.
- C. The same incident may occur in the future.
- D. Service level agreements (SLAs) may not be met.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 376
An IS auditor concludes that an organization has a quality security policy. Which of the following is MOST important to determine next? The policy must be:

- A. updated frequently.
- B. developed by process owners.
- C. based on industry standards.
- D. well understood by all employees.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 377
When determining which IS audits to conduct during the upcoming year, internal audit has received a request from management for multiple audits of the contract division due to fraud findings during the prior year. Which of the following is the BEST basis for selecting the audits to be performed?

- A. Select audits based on an organizational risk assessment.
- B. Select audits based on collusion risk.
- C. Select audits based on the skill sets of the IS auditors.
- D. Select audits based on management's suggestion.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 378
An organization is considering the implementation of a business application. The IS auditor should FIRST ensure that:

- A. user requirements are used to select the vendor.
- B. an approved business case is in place.
- C. users are represented on the project management team.
- D. security requirements are specified.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 379

An IS auditor discovers an option in a database that allows the administrator to directly modify any table. This option is necessary to overcome bugs in the software, but is rarely used. Changes to tables are automatically logged. The IS auditor's FIRST action should be to:

- A. determine whether the log of changes to the tables is backed up.
- B. determine whether the audit trail is secured and reviewed.
- C. recommend that the option to directly modify the database be removed immediately.
- D. recommend that the system require two persons to be involved in modifying the database.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 380

Which of the following provides an IS auditor with the BEST evidence that an organization's information security program is aligned to business objectives?

- A. Balanced scorecard
- B. Risk assessment results
- C. Business impact analysis (BIA)
- D. Cost-benefit analysis

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 381

An IS auditor is planning an audit of an organization's payroll processes. Which of the following is the BEST procedure to provide assurance against internal fraud?

- A. Review management's approval of payroll system changes.
- B. Review management's validation of payroll payment recipients.
- C. Interview the payroll manager to obtain a detailed process workflow.
- D. Compare employee work contracts against hours entered in the payroll system.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 382

An IS auditor has been asked to review an event log aggregation system to ensure risk management practices have been applied. Which of the following should be of MOST concern to the auditor?

- A. Completeness testing has not been performed on the log data.
- B. Data encryption standards have not been considered.
- C. Log feeds are uploaded via batch process.
- D. The log data is not normalized.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 383

An IS auditor is planning a risk-based audit of the human resources department. The department uses separate systems for its payroll, training and employee performance review functions. What should the IS auditor do FIRST before identifying the key controls to be tested?

- A. Determine the inherent risk related to each system.
- B. Determine the number of samples to be tested for each system.
- C. Assess the control risk associated with each system.
- D. Identify the technical skills and resources needed to audit each system.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 384

Which of the following findings should be of GREATEST concern to an IS auditor performing a review of IT operations?

- A. The job scheduler application has not been designed to display pop-up error messages.
- B. Access to the job scheduler application has not been restricted to a maximum of two staff members.
- C. Changes to the job scheduler application's parameters are not approved and reviewed by an operations supervisor.
- D. Operations shift turnover logs are not utilized to coordinate and control the processing environment.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 385

Which of the following findings should be of MOST concern to an IS auditor reviewing an organization's business continuity plan (BCP)?

- A. An application inventory is not included.
- B. A resource optimization plan is not included.
- C. A business feasibility study was not performed.
- D. A business impact analysis (NA) was not performed.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 386

Which of the following is the BEST way for an external IS auditor to determine the scope of an audit for a large multinational organization?

- A. Focus on areas related to the use of emerging technologies.
- B. Sample audit each geographical location.
- C. Focus on identified high-risk areas in the organization.
- D. Use the work of the internal auditor at each location.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 387

After the merger of two organizations, which of the following is the MOST important task for an IS auditor to perform?

- A. Investigating access rights for expiration dates
- B. Verifying that access privileges have been reviewed
- C. Updating the security policy
- D. Updating the continuity plan for critical resources

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 388

Which of the following should be an IS auditor's PRIMARY focus when evaluating the response process for cyber crimes?

- A. Notification to regulators
- B. Communication with law enforcement
- C. Evidence collection
- D. Root cause analysis

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 389

During the course of an audit, an IS auditor's organizational independence is impaired. The IS auditor should FIRST:

- A. inform audit management of the situation.
- B. inform senior management in writing and proceed with the audit.
- C. obtain the auditee's approval before continuing the audit.
- D. proceed with the audit as planned after documenting the incident.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 390

An IS auditor has identified that some IT staff have administrative access to the enterprise resource planning (ERP) application, database, and server. IT management has responded that due to limited resources, the same IT staff members have to support all three layers of the ERP application. Which of the following would be the auditor's BEST recommendation to management?

- A. Request funding to hire additional IT staff to enable segregation of duties.

- B. Leverage business unit personnel to serve as administrators of the application.
- C. Monitor activities of the associated IT staff members by reviewing system-generated logs weekly.
- D. Remove some of the administrative access of the associated IT staff members.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 391

Which of the following would provide the BEST evidence for an IS auditor to determine whether segregation of duties is in place?

- A. A review of the organizational chart
- B. A review of personnel files
- C. An analysis of user access requests
- D. A walk-through of job functions

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 392

An IS auditor notes that a number of application plug-ins currently in use are no longer supported. Which of the following is the auditor's BEST recommendation to management?

- A. Implement role-based access controls.
- B. Conduct a vulnerability assessment to determine exposure.
- C. Review content backup and archiving procedures.
- D. Review on-boarding and off-boarding processes.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 393

What should be the PRIMARY basis for scheduling a follow-up audit?

- A. The significance of reported findings
- B. The completion of all corrective actions
- C. The availability of audit resources
- D. The time elapsed after audit report submission

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 394

The PRIMARY purpose for an IS auditor to review previous audit reports during the planning phase of a current audit is to:

- A. become informed about the auditee's business processes.
- B. adjust audit scope to reduce testing in areas related to previous findings.
- C. identify applicable regulatory requirements for the current audit.
- D. ensure that previously identified risks are addressed in the audit program.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 395

What should be an IS auditor's NEXT course of action when a review of an IT organizational structure reveals IT staff members have duties in other departments?

- A. Determine whether any segregation of duties conflicts exist.
- B. Recommend that segregation of duties controls be implemented.
- C. Report the issue to human resources (HR) management.
- D. Immediately report a potential finding to the audit committee.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 396

An IS auditor is assessing an organization's implementation of a virtual network. Which of the following observations should be considered the MOST significant risk?

- A. Communication performance over the virtual network is not monitored.
- B. Virtual network devices are replicated and stored in offline mode.

- C. Traffic over the virtual network is not visible to security protection devices.
- D. Physical and virtual network configurations are not managed by the same team.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 397

An IS auditor is assessing a recent migration of mission critical applications to a virtual platform. Which of the following observations poses the GREATEST risk to the organization?

- A. A post-implementation review of the hypervisor has not yet been conducted.
- B. Role descriptions do not accurately reflect new virtualization responsibilities.
- C. The migration was not approved by the board of directors.
- D. Training for staff with new virtualization responsibilities has not been conducted.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 398

Which of the following should be of MOST concern to an IS auditor evaluating a forensics program?

- A. Forensic images are stored on removable media with encryption.
- B. Forensic images are only stored for involuntarily terminated employees.
- C. Forensic images are only maintained for 12 months.
- D. Forensic images are stored on shared disks.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 399

An organization has recently acquired and implemented intelligent-agent software for granting loans to customers. During the post-implementation review, which of the following would be the KEY procedure for the IS auditor to perform?

- A. Review input and output control reports to verify the accuracy of the system decisions.
- B. Review system documentation to ensure completeness.
- C. Ensure that a detection system designed to verify transaction accuracy is included.
- D. Review signed approvals to ensure responsibilities for decisions of the system are well-defined.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 400

Which of the following should be of GREATEST concern when conducting an audit of software inventory management?

- A. Missing licensing paper contracts
- B. Anti-virus software not regularly upgraded
- C. Unlicensed software
- D. Development libraries not included in inventory records

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 401

Which of the following would the IS auditor MOST likely review to determine whether modifications to the operating system parameters were authorized?

- A. Change control log
- B. System initialization logs
- C. Security system parameters
- D. Documentation of exit routines

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 402

Which of the following is the BEST source of information for an IS auditor to use when determining whether an organization's information security policy is adequate?

- A. Industry benchmarks
- B. Information security program plans

- C. Penetration test results
- D. Risk assessment results

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 403

An internal audit has revealed a large number of incidents for which root cause analysis has not been performed. Which of the following is MOST important for the IS auditor to verify to determine whether there is an audit issue?

- A. Cost of resolving the incidents
- B. Severity level of the incidents
- C. Time required to resolve the incidents
- D. Frequency of the incidents

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 404

In an IS auditor's review of an organization's configuration management practices for software, which of the following is MOST important?

- A. Service level agreements (SLAs) between the IT function and users
- B. Post-implementation review reports from development efforts
- C. Organizational policies related to release management
- D. Software rental contracts or lease agreements

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 405

An IS auditor notes that due to the small size of the organization, human resources staff can create new employees in the payroll system as well as process payroll. Which of the following is the BEST recommendation to address this situation?

- A. Outsource the processing of payroll to a third party.
- B. Implement a periodic user access review over the payroll system.
- C. Implement periodic reviews of employees in the payroll system.
- D. Hire additional staff so that access for the two functions can be segregated.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 406

Which of the following is MOST important for an auditor to consider when scoping for an IT general controls audit?

- A. Frequency of changes
- B. Timing of changes
- C. Types of changes
- D. Number of changes

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 407

What would be an IS auditor's BEST course of action when a critical issue outside the audit scope is discovered on an employee workstation?

- A. Take no action as this issue is outside the audit scope.
- B. Expand the audit scope to include desktop audits.
- C. Include the findings with recommendations in the final report.
- D. Record the observation in the workpapers.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 408

During an ongoing audit, management requests a briefing on the findings to date. Which of the following is the IS auditor's BEST course of action?

- A. Review working papers with the auditee.
- B. Request the auditee provide management responses.
- C. Request management wait until a final report is ready for discussion.

D. Present observations for discussion only.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 409

An IS auditor finds that an employee lost a mobile device containing sensitive company data. Which of the following would have BEST prevented data leakage?

- A. The employee promptly reported the lost device.
- B. Data on the device was encrypted.
- C. The employee acknowledged the acceptable use policy.
- D. Data on the device was backed up.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 410

Which of the following is the PRIMARY purpose for external assessments of internal audit's quality assurance systems and frameworks?

- A. To provide assurance that the internal audit function conforms with established professional practices
- B. To provide assurance that internal audit staff are qualified to perform their responsibilities
- C. To confirm the accuracy and reliability of prior internal audit results
- D. To confirm the internal audit department has adequate budget to perform its duties

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 411

Which of the following reports would BEST assist an IS auditor evaluating the effectiveness of preventive maintenance?

- A. Downtime
- B. Help desk
- C. Violation
- D. Activity

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 412

During an audit of an online sales booking system, the IS auditor identifies exceptions in the batch mode that cause some transactions to not get posted. Which of the following is MOST important for the auditor to review?

- A. Error detection and handling procedures
- B. Changes to the scheduling program
- C. The vulnerability of source code and parameters configured
- D. The nature and frequency of network connection failures

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 413

Which of the following would BEST indicate the independence of the internal audit function?

- A. Engagement letter
- B. Audit charter
- C. Organizational structure
- D. Dedicated chief internal auditor

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 414

Which audit approach is MOST helpful in optimizing the use of IS audit resources?

- A. Agile auditing
- B. Outsourced auditing
- C. Risk-based auditing
- D. Continuous auditing

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 415

Which of the following should an IS auditor review when verifying the integrity of a relational database management system (RDBMS)?

- A. Cyclic redundancy check value
- B. Secret key algorithm used
- C. Foreign key attributes
- D. Database size value

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 416

The PRIMARY benefit of a risk-based audit methodology is to:

- A. reduce audit scope.
- B. identify key controls.
- C. understand business processes.
- D. prioritize audit resources.

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 417

Following an internal audit of a database, management has committed to enhance password management controls. Which of the following provides the BEST evidence that management has remediated the audit finding?

- A. Screenshots from end users showing updated password settings
- B. Interviews with management about remediation completion
- C. Change tickets of recent password configuration updates
- D. Observation of updated password settings with database administrators (DBAs)

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 418

Which of the following is the BEST audit technique to identify fraudulent activity processing system?

- A. Inspect flow and timing of authorizations recorded by the system.
- B. Perform statistical analysis and classification of all transactions.
- C. Inspect the source code of the application programs.
- D. Review a sample of transactions for compliance with policies.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 419

The PRIMARY reason to formally communicate audit results immediately after the audit has been completed is to ensure:

- A. the report is relevant and useful.
- B. deadlines and departmental goals are met.
- C. the risk identified in the report is immediately mitigated.
- D. the auditors adhere to standard audit practices.

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 420

Which of the following findings should be of GREATEST concern to an IS auditor conducting a forensic analysis following incidents of suspicious activities on a server?

- A. Most suspicious activities were created by system IDs.
- B. Audit logs are not enabled on the server.
- C. The server's operating system is outdated.
- D. The server is outside the domain.

Correct Answer: B
Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 421

An IS auditor notes that nightly batch processing is frequently incomplete for an application. The auditor should FIRST review controls over which of the following?

- A. Application logs
- B. Backup procedures
- C. Job notification
- D. Job scheduling

Correct Answer: D

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 422

What is the PRIMARY benefit of an audit approach which requires reported findings to be issued together with related action plans, owners, and target dates?

- A. It establishes accountability for the action plans
- B. It helps to ensure factual accuracy of finding
- C. It enforces action plan consensus between auditors and auditees
- D. It facilitates easier audit follow-up

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 423

Which of the following is the MOST important objective of a risk assessment performed during the annual audit planning process?

- A. Identifying key areas of focus
- B. Eliminating areas with low residual risk
- C. Engaging management in the audit planning process
- D. Assigning audit resources

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 424

An IS audit manager has been advised that hackers have entered the company's e-commerce server a number of times in the past month. The IS audit group does not have the expertise necessary to investigate this situation. The IS audit manager should:

- A. obtain support by contracting external resources.
- B. have network security staff conduct the audit.
- C. have IS management proceed immediately with control self-assessment (CSA).
- D. decline the request on the basis that the staff is not prepared for the task.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 425

During an internal review of the system development life cycle management, an IS auditor finds that customer production data has been displayed in the user acceptance testing (UAT) environment. Which of the following is the auditor's BEST recommendation?

- A. Request approval for the use of production data in the UAT environment
- B. Use de-identified data in the UAT environment.
- C. Use data encryption in the UAT environment.
- D. Perform a risk assessment to establish the impact of data leakage.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 426

An IS auditor finds that capacity management for a key system is being performed by IT with no input from the business. The auditor's PRIMARY concern would be:

- A. unanticipated increase in business's capacity needs
- B. impact to future business project funding
- C. failure to maximize the use of equipment
- D. cost of excessive data center storage capacity

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 427

An IS auditor is reviewing an end-user computing program. Which of the following is the BEST way to maintain the accuracy of calculations embedded in the tool?

- A. Assign an owner and developer for each tool.
- B. Maintain version control.
- C. Review calculations periodically.
- D. Use standardized tool calculations.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 428

An IS auditor identifies that the accounts payable clerk has direct access to the payment file after it has been generated. The MOST significant risk to the organization is that payments may be:

- A. rejected.
- B. duplicated.
- C. late to customers.
- D. altered.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 429

An IS auditor finds an IT department does not perform periodic discovery of hardware and software deployed in an environment. What is the GREATEST associated risk?

- A. Increase in unused licenses within the organization
- B. Inaccurate inventory of hardware and software
- C. Inaccurate cost estimates of hardware and software
- D. Incomplete lists for third-party license audits

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 430

An IS auditor is conducting an interim review of an IT project. Which of the following would provide the MOST useful information regarding project performance?

- A. Milestone review
- B. Earned value analysis
- C. Cost-benefit analysis
- D. Function point analysis

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 431

While reviewing transactions, an IS auditor discovers inconsistencies in a relational database. Which of the following would be the auditor's BEST recommendation?

- A. Perform data modeling.
- B. Re-index the database.
- C. Normalize the database.
- D. Implement edit checks.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 432

Which of the following would be MOST useful to an IS auditor confirming that an IS department meets its service level agreements (SLAs)?

- A. System downtime reports
- B. IS strategic plan
- C. Capacity planning tools
- D. System utilization reports

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 433

Which of the following would an IS auditor MOST likely recommend to ensure that an organization's IT systems are effectively kept up-to-date regarding vulnerabilities?

- A. Release management
- B. Version management
- C. Patch management
- D. Risk management

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 434

What should be of MOST concern to an IS auditor reviewing an organization's proposal to combine its online transaction processing (OLTP) data and data warehouse in the same database environment?

- A. The quality of business intelligence reporting may be impacted.
- B. A significant amount of data computing resources will be required.
- C. The combination of static data with dynamic data could reduce data quality.
- D. The complexity of the solution could lead to delays in deployment.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 435

An IS auditor has found that despite an increase in phishing attacks over the past two years, there has been a significant decrease in the success rate. Which of the following is the MOST likely reason for this decline?

- A. Implementation of an intrusion detection system (IDS)
- B. Development of an incident response plan
- C. Enhanced training for incident responders
- D. Implementation of a security awareness program

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 436

An IS auditor is evaluating networked devices at one of the organization's branch locations. Which of the following observations should be of GREATEST concern?

- A. Personal devices are required to connect wirelessly to a guest network.
- B. A local executive has a wireless-enabled fish tank connected to the corporate network.
- C. Company laptops with built-in cameras are observed with opaque tape blocking the cameras.
- D. Four personal laptops with default passwords are connected to the corporate network.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 437

An external IS auditor is reviewing the continuous monitoring system for a large bank and notes several potential issues. Which of the following would present the GREATEST concern regarding the reliability of the

monitoring system?

- A. The system results are not regularly reviewed by management.
- B. The measurement method is periodically varied.
- C. The monitoring system was configured by internal auditors.
- D. The alert threshold is updated periodically.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 438

Which of the following BEST indicates to an IS auditor that an IT-related project will deliver value to the organization?

- A. The cost of the project is within the organization's risk appetite.
- B. The project will use existing infrastructure to deliver services.
- C. Competitors are considering similar IT-based solutions.
- D. Requirements are based on stakeholder expectations.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 439

An IS auditor reviewing a financial organization's identity management solution found that some critical business applications do not have identified owners. Which of the following should the auditor do NEXT?

- A. Request a business risk acceptance.
- B. Discuss the issue with the auditee.
- C. Write a finding in the audit report.
- D. Revoke access rights to the critical applications.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 440

An IS audit team is planning to rely on a system-generated report to reduce the substantive procedures they will need to perform. Which of the following procedures should the IS auditor perform to verify the completeness of the report?

- A. Test data for appropriateness.
- B. Validate the report query.
- C. Establish some criteria for expected results and compare to actual results.
- D. Trace a sample of transactions to the internal transactions.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 441

What is the BEST strategy to prioritize work when planning a follow-up audit?

- A. Target risks that are most easily mitigated.
- B. Agree on priorities with risk owners.
- C. Target the areas of highest risk.
- D. Target risks not reported as mitigated by risk owners.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 442

Which of the following should be established FIRST when initiating a control self-assessment (CSA) program in a small organization?

- A. Control register
- B. Staff questionnaires
- C. Assessor competency
- D. Facilitated workshops

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 443

Which of the following is the MOST appropriate responsibility of an IS auditor involved in a data center renovation project?

- A. Performing independent reviews of responsible parties engaged in the project
- B. Ensuring the project progresses as scheduled and milestones are achieved
- C. Shortlisting vendors to perform renovations
- D. Approving the design of controls for the data center

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 444

Which of the following should an IS auditor review FIRST when evaluating a business process for auditing?

- A. Evidence that IS-related controls are operating effectively
- B. Competence of the personnel performing the process
- C. Assignment of responsibility for process management
- D. Design and implementation of controls

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 445

Which of the following is the MOST important operational aspect for an IS auditor to consider when assessing an assembly line with quality control sensors accessible via wireless technology?

- A. Device updates
- B. Resource utilization
- C. Device security
- D. Known vulnerabilities

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 446

During an audit of an access control system, an IS auditor finds that RFID card readers are not connected via the network to a central server. Which of the following is the GREATEST risk associated with this finding?

- A. Lost or stolen cards cannot be disabled immediately.
- B. Card reader firmware updates cannot be rolled out automatically.
- C. The system is not easily scalable to accommodate a new device.
- D. Incidents cannot be investigated without a centralized log file.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 447

Which of the following findings should be of GREATEST concern to an IS auditor reviewing the effectiveness of an organization's problem management practices?

- A. Problem records are prioritized based on the impact of incidents.
- B. Some incidents are closed without problem resolution.
- C. Root causes are not adequately identified.
- D. Problems are frequently escalated to management for resolution.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 448

A review of IT interface controls finds an organization does not have a process to identify and correct records that do not get transferred to the receiving system. Which of the following is the IS auditor's BEST recommendation?

- A. Implement software to perform automatic reconciliations of data between systems.
- B. Enable automatic encryption, decryption, and electronic signing of data files.
- C. Have coders perform manual reconciliation of data between systems.
- D. Automate the transfer of data between systems as much as feasible.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 449

An IS auditor notes that IT and the business have different opinions on the availability of their application servers. Which of the following should the IS auditor review FIRST in order to understand the problem?

- A. The regular performance-reporting documentation
- B. The exact definition of the service levels and their measurement
- C. The alerting and measurement process on the application servers
- D. The actual availability of the servers as part of a substantive test

Correct Answer: B

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 450

When evaluating the management practices at a third-party organization providing outsourced services, the IS auditor considers relying on an independent auditor's report. The IS auditor would FIRST:

- A. review the objectives of the audit.
- B. examine the independent auditor's workpapers.
- C. discuss the report with the independent auditor.
- D. determine if recommendations have been implemented.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 451

When an organization introduces virtualization into its architecture, which of the following should be an IS auditor's PRIMARY area of focus to verify adequate protection?

- A. Maintenance cycles
- B. Multiple versions of the same operating system
- C. Shared storage space
- D. Host operating system configuration

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 452

An IS auditor is reviewing a banking mobile application that allows end users to perform financial transactions. Which of the following poses a security risk to the organization?

- A. Unpatched security vulnerabilities in the mobile operating system
- B. Outdated mobile network settings
- C. Application programming interface (API) logic faults
- D. Lack of strong device passwords

Correct Answer: A

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 453

Which of the following is the BEST way for an IS auditor to reduce sampling risk when performing audit sampling to verify the adequacy of an organization's internal controls?

- A. Outsource the sampling process.
- B. Decrease the sampling size.
- C. Lower the sample standard deviation.
- D. Use a statistical sampling method.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 454

A company laptop has been stolen, and all photos on the laptop have been published on social media. Which of the following is the IS auditor's BEST course of action?

- A. Ensure that the appropriate authorities have been notified.
- B. Review the photos to determine whether they were for business or personal purposes.
- C. Verify the organization's incident reporting policy was followed.
- D. Determine if the laptop had the appropriate level of encryption.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 455

An organization's enterprise architecture (EA) department decides to change a legacy system's components while maintaining its original functionality. Which of the following is MOST important for an IS auditor to understand when reviewing this decision?

- A. The current business capabilities delivered by the legacy system
- B. The database entity relationships within the legacy system
- C. The data flows between the components to be used by the redesigned system
- D. The proposed network topology to be used by the redesigned system

Correct Answer: C

Explanation**Explanation/Reference:**

Section: The process of Auditing Information System

QUESTION 456

During an internal audit review of a human resources (HR) recruitment system implementation, the IS auditor notes that several defects were unresolved at the time the system went live. Which of the following is the auditor's MOST important task prior to formulating an audit opinion?

- A. Confirm the project plan was approved.
- B. Confirm the severity of the identified defects.
- C. Review the user acceptance test (UAT) results for defects.
- D. Review the initial implementation plan for timelines.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 457

Which of the following observations should be of GREATEST concern to an IS auditor reviewing a hosted virtualized environment where each guest operating system (OS) is running a production application?

- A. All virtual machines are launching an application backup job at the same time.
- B. There are file shares between the host OS and the guest OS.
- C. Access to virtualization utilities and tools in the host is not restricted.
- D. The test environment of the applications is in a separate guest OS.

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 458

A multinational organization is integrating its existing payroll system with a human resource information system. Which of the following should be of GREATEST concern to the IS auditor?

- A. Currency conversion
- B. Scope creep
- C. Application interfaces
- D. System documentation

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 459

Which of the following is the MOST effective sampling method for an IS auditor to use for identifying fraud and circumvention of regulations?

- A. Stop-or-go sampling
- B. Variable sampling
- C. Discovery sampling
- D. Statistical sampling

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System
This is an example of the discovery sampling technique, where an auditor examines samples until an exception is found.

QUESTION 460

Which of the following is the BEST way for an IS auditor to maintain visibility of a new system implementation project when faced with resource limitations?

- A. Evaluate the project plan and milestones.
- B. Attend steering committee meetings.
- C. Assess user acceptance test (UAT) results.
- D. Review the target control environment .

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 461

An IS auditor's independence with respect to the audit of an application system is MOST likely to be impaired if the auditor:

- A. performed a development review of the application.
- B. designed an embedded audit module for the application.
- C. knows that the application contains the auditor's personal transactions.
- D. reports to an individual responsible for the application.

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 462

Which of the following provides the MOST useful information to an IS auditor reviewing the relationships between critical business processes and IT systems?

- A. IT portfolio management
- B. IT service management
- C. Enterprise architecture (EA)
- D. Configuration management database (CMDB)

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 463

Which of the following is the BEST justification for deferring remediation testing until the next audit?

- A. Auditee management has accepted all observations reported by the auditor.
- B. The audit environment has changed significantly.
- C. The auditor who conducted the audit and agreed with the timeline has left the organization.
- D. Management's planned actions are sufficient given the relative importance of the observations.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 464

When performing a post-implementation review, the adequacy of the data conversion effort would BEST be evaluated by performing a thorough review of the:

- A. functional conversion rules.
- B. conversion user acceptance testing (UAT) results.
- C. go-live conversion results.
- D. detailed conversion approach templates.

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 465

Which of the following is a PRIMARY role of an IS auditor in a control self-assessment (CSA) workshop?

- A. Reporting results of the workshop and recommendations to management
- B. Gathering background information prior to the SA workshop
- C. Analyzing gaps between control design and control framework
- D. Assisting participants in evaluating risks and relevant controls

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 466

An IS auditor is planning an audit of an organization's accounts payable processes. Which of the following controls is MOST important to assess in the audit?

- A. Management review and approval of purchase orders
- B. Management review and approval of authorization tiers
- C. Segregation of duties between issuing purchase orders and making payments
- D. Segregation of duties between receiving invoices and setting authorization limits

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 467

Which of the following should be of GREATEST concern to an IS auditor conducting a security review of a point-of-sale (POS) system?

- A. Management of POS systems is outsourced to a vendor based in another country.
- B. POS systems are not integrated with accounting applications for data transfer.
- C. Credit card verification value (CVV) information is stored on local POS systems.
- D. An optical scanner is not used to read bar codes for generating sales invoices.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 468

External experts were used on a recent IT audit engagement. While assessing the external experts' work, the internal audit team found some gaps in the evidence that may have impacted their conclusions. What is the internal audit team's BEST course of action?

- A. Engage another expert to conduct the same testing.
- B. Recommend the external experts conduct additional testing.
- C. Report a scope limitation in their conclusions.
- D. Escalate to senior management.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 469

Which of the following is the BEST ensures the quality and integrity of test procedures used in audit analytics?

- A. Developing and communicating test procedure best practices to audit teams
- B. Decentralizing procedures and implementing periodic peer review
- C. Developing and implementing an audit data repository
- D. Centralizing procedures and implementing change control

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 470

After delivering an audit report, the audit manager discovers that evidence was overlooked during the audit. This evidence indicates that a procedural control may have failed and could contradict a conclusion of the audit. Which of the following risks is MOST affected by this oversight?

- A. Inherent
- B. Financial
- C. Audit
- D. Operational

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 471

Which of the following should be the FIRST step when planning an IS audit of a third-party service provider that monitors network activities?

- A. Evaluate the organization's third-party monitoring process
- B. Determine if the organization has a secure connection to the provider
- C. Review the roles and responsibilities of the third-party provider
- D. Review the third party's monitoring logs and incident handling

Correct Answer: A

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 472

An IS auditor is evaluating an organization's IT strategy and plans. Which of the following would be of GREATEST concern?

- A. There is inadequate documentation of IT strategic planning
- B. IT is not engaged in business strategic planning
- C. There is not a defined IT security policy
- D. The business strategy meeting minutes are not disturbing

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 473

An IS auditor is reviewing an industrial control system (ICS) that uses older unsupported technology in the scope of an upcoming audit. What should the auditor consider the MOST significant concern?

- A. Technical specifications are not documented.
- B. Disaster recovery plans (DRPs) are not in place.
- C. Attack vectors are evolving for industrial control systems.
- D. There is a greater risk of system exploitation.

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 474

Which of the following is an IS auditor's BEST recommendation to help an organization increase the efficiency of computing resources?

- A. Hardware upgrades
- B. Virtualization
- C. Real-time backups
- D. Overclocking the central processing unit (CPU)

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 475

An IS audit manager was temporarily tasked with supervising a project manager assigned to the organization's payroll application upgrade. Upon returning to the audit department, the audit manager has been asked to perform an audit to validate the implementation of the payroll application. The audit manager is the only one in the audit department with IT project management experience. What is the BEST course of action?

- A. Transfer the assignment to a different audit manager despite lack of IT project management experience
- B. Have a senior IS auditor manage the project with the IS audit manager performing final review
- C. Outsource the audit to independent and qualified resources
- D. Manage the audit since there is no one else with the appropriate experience

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 476

Internal audit is conducting an audit of customer transaction risk. Which of the following would be the BEST reason to use data analytics?

- A. Transactional data is contained in multiple discrete systems that have varying levels of reliability
- B. Anomalies and risk trends in the data set have yet to be defined
- C. The audit is being performed to comply with regulations requiring periodic random sample testing
- D. The audit focus is on a small number of predefined high-risk transactions

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 477

When reviewing a data classification scheme, it is MOST important for an IS auditor to determine if:

- A. each information asset is assigned to a different classification.
- B. senior IT managers are identified as information owners.
- C. the security criteria are clearly documented for each classification.
- D. the information owner is required to approve access to the asset.

Correct Answer: C

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 478

An IS auditor is examining a front-end subledger and a main ledger. Which of the following would be the GREATEST concern if there are flaws in the mapping of accounts between two systems?

- A. Unauthorized alteration of account attributes
- B. Inaccuracy of financial reporting
- C. Inability to support new business transactions
- D. Double-posting of a single journal entry

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 479

Which of the following is the PRIMARY purpose of conducting follow-up audits for material observations?

- A. To validate the correctness of reported findings
- B. To assess the risk of the audit environment
- C. To assess evidence for management reporting
- D. To validate remediation efforts

Correct Answer: D

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 480

What is the MAIN purpose of an organization's internal IS audit function?

- A. Provide assurance to management about the effectiveness of the organization's risk management and internal controls.
- B. Identify and initiate necessary changes in the control environment to help ensure sustainable improvement.
- C. Review the organization's policies and procedures against industry best practice and standards.
- D. Independently attest the organization's compliance with applicable legal and regulatory requirements.

Correct Answer: B

Explanation

Explanation/Reference:

Section: The process of Auditing Information System

QUESTION 481

An IS auditor informed that several spreadsheets are being used to generate key financial information. What should the auditor verify FIRST?

- A. Whether the spreadsheets meet the minimum IT general controls requirements
- B. Whether the spreadsheets are being formally reviewed by the chief financial officer (CFO)
- C. Whether there is a complete inventory of end-user computing (EUC) spreadsheets
- D. Whether adequate documentation and training is available for spreadsheets users

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 482
Which of the following should be the PRIMARY role of an internal audit function in the management of identified business risks?

- A. Operating the risk management framework
- B. Establishing a risk appetite
- C. Establishing a risk management framework
- D. Validating enterprise risk management (ERM)

Correct Answer: D
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 483
A bank's web-hosting provider has just completed an internal IT security audit and provides only a summary of the findings to the bank's auditor. Which of the following should be the bank's GREATEST concern?

- A. The bank's auditors are not independent of the service provider
- B. The audit scope may not have addressed critical areas
- C. The audit may be duplicative of the bank's internal audit procedures
- D. The audit procedures are not provided to the bank

Correct Answer: A
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 484
An IS audit manager is preparing the staffing plan for an audit engagement of a cloud service provider. What should be the manager's PRIMARY concern when made aware that a new auditor in the department previously worked for this provider?

- A. Competency
- B. Independence
- C. Integrity
- D. Professional conduct

Correct Answer: C
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 485
An IS auditor noted that a change to a critical calculation was placed into the production environment without being tested. Which of the following is the BEST way to obtain assurance that the calculation functions correctly?

- A. Check regular execution of the calculation batch job
- B. Perform substantive testing using computer-assisted audit techniques (CAATs)
- C. Obtain post-change approval from management
- D. Interview the lead system developer

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 486
What would be of GREATEST concern to an IS auditor reviewing end-user computing (EUC) spreadsheets used for financial reporting in which version control is enforced?

- A. Access requests are processed manually
- B. Spreadsheets are maintained in various locations
- C. Spreadsheet owners are only reviewed annually
- D. Spreadsheets are not password protected

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 487

Which of the following should be of GREATEST concern to an IS auditor planning to employ data analytics in an upcoming audit?

- A. There is no documented data model
- B. Data is from the previous reporting period
- C. Available data is incomplete
- D. Data fields are used for multiple purposes

Correct Answer: B
Explanation

Explanation/Reference:
Section: The process of Auditing Information System

QUESTION 488

Which of the following requires a consensus by key stakeholders on IT strategic goals and objectives?

- A. Balanced scorecards
- B. Benchmarking
- C. Maturity models
- D. Peer reviews

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 489

An IS auditor found that a company executive is encouraging employee use of social networking sites for business purposes. Which of the following recommendations would BEST help to reduce the risk of data leakage?

- A. Requiring policy acknowledgment and nondisclosure agreements signed by employees
- B. Providing education and guidelines to employees on use of social networking sites
- C. Establishing strong access controls on confidential data
- D. Monitoring employees' social networking usage

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 490

An organization's information security department is creating procedures for handling digital evidence that may be used in court. Which of the following would be the MOST important consideration from a risk standpoint?

- A. Ensuring the entire security team reviews the evidence
- B. Ensuring that analysis is conducted on the original data
- C. Ensuring the original data is kept confidential
- D. Ensuring the integrity of the data is preserved

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 491

Which of the following is the BEST approach to make strategic information security decisions?

- A. Establish regular information security status reporting
- B. Establish business unit security working groups
- C. Establish periodic senior management meetings
- D. Establish an information security steering committee

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 492

An organization which uses external cloud services extensively is concerned with risk monitoring and timely response. The BEST way to address this concern is to ensure:

- A. the availability of continuous technical support
- B. internal security standards are in place
- C. a right-to-audit clause is included in contracts
- D. appropriate service level agreements (SLAs) are in place

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 493

The MAIN purpose of documenting information security guidelines for use within a large, international organization is to:

- A. ensure that all business units have the same strategic security goals
- B. provide evidence for auditors that security practices are adequate
- C. explain the organization's preferred practices for security
- D. ensure that all business units implement identical security procedures

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 494

Which of the following would be the MOST important information to include in a business case for an information security project in a highly regulated industry?

- A. Industry comparison analysis
- B. Critical audit findings
- C. Compliance risk assessment
- D. Number of reported security incidents

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 495

When an information security manager presents an information security program status report to senior management, the MAIN focus should be:

- A. key performance indicators (KPIs)
- B. critical risks indicators
- C. net present value (NPV)
- D. key controls evaluation

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 496

An organization's senior management is encouraging employees to use social media for promotional purposes. Which of the following should be the information security manager's FIRST step to support this strategy?

- A. Develop a business case for a data loss prevention solution
- B. Develop a guideline on the acceptable use of social media
- C. Incorporate social media into the security awareness program
- D. Employ the use of a web content filtering solution

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 497

Which of the following is the BEST course of action for an information security manager to align security and business goals?

- A. Reviewing the business strategy
- B. Actively engaging with stakeholders
- C. Conducting a business impact analysis
- D. Defining key performance indicators

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 498

An organization faces severe fines and penalties if not in compliance with local regulatory requirements by an established deadline. Senior management has asked the information security manager to prepare an action plan to achieve compliance. Which of the following would provide the MOST useful information for planning purposes?

- A. Results from a business impact analysis
- B. Results from a gap analysis
- C. An inventory of security controls currently in place
- D. Deadline and penalties for noncompliance

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 499

The MOST important objective of security awareness training for business staff is to:

- A. understand intrusion methods
- B. reduce negative audit findings
- C. increase compliance
- D. modify behavior

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 500

If the inherent risk of a business activity is higher than the acceptable risk level, the information security manager should FIRST:

- A. transfer risk to a third party to avoid cost of impact
- B. implement controls to mitigate the risk to an acceptable level
- C. recommend that management avoids the business activity
- D. assess the gap between current and acceptable level of risk

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 501

Which of the following is the MOST important driver when developing an effective information security strategy?

- A. Security audit reports
- B. Benchmarking reports
- C. Information security standards
- D. Compliance requirements

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 502

The FIRST step in establishing an information security program is to:

- A. secure organizational commitment and support
- B. assess the organization's compliance with regulatory requirements
- C. determine the level of risk that is acceptable to senior management
- D. define policies and standards that mitigate the organization's risks

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 503

Which of the following is the BEST reason to certify an organization to an international security standard?

- A. The certification covers enterprise security end-to-end.
- B. The certification reduces information security risk.
- C. The certification ensures that optimal controls are in place.
- D. The certification delivers value to stakeholders.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 504

An organization is considering whether to allow employees to use personal computing devices for business purposes. To BEST facilitate senior management's decision, the information security manager should:

- A. perform a cost-benefit analysis
- B. map the strategy to business objectives
- C. conduct a risk assessment
- D. develop a business case

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 505

A PRIMARY advantage of involving business management in evaluating and managing information security risks is that they:

- A. better understand the security architecture
- B. better understand organizational risks

- C. can balance technical and business risks
- D. are more objective than security management

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 506

Which of the following is the MOST effective way for an organization to ensure its third-party service providers are aware of information security requirements and expectations?

- A. Providing information security training to third-party personnel
- B. Auditing the service delivery of third-party providers
- C. Inducting information security clauses within contracts
- D. Requiring third parties to sign confidentiality agreements

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 507

Which of the following should be the MOST important consideration when implementing an information security framework?

- A. Compliance requirements
- B. Audit findings
- C. Technical capabilities
- D. Risk appetite

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 508

An organization's IT department is undertaking a large virtualization project to reduce its physical server footprint. Which of the following should be the HIGHEST priority of the information security manager?

- A. Determining how incidents will be managed
- B. Selecting the virtualization software
- C. Being involved as the design stage of the project
- D. Ensuring the project has appropriate security funding

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 509

An information security manager is developing evidence preservation procedures for an incident response plan. Which of the following would be the BEST source of guidance for requirements associated with the procedures?

- A. IT management
- B. Executive management
- C. Legal counsel
- D. Data owners

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 510

What is the MOST important role of an organization's data custodian in support of information security function?

- A. Evaluating data security technology vendors
- B. Applying approval security policies
- C. Approving access rights to departmental data
- D. Assessing data security risks to the organization

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 511

An information security manager has identified and implemented migrating controls according to industry best practices. Which of the following is the GREATEST risk associated with this approach?

- A. Important security controls may be missed without senior management input.
- B. The cost of control implementation may be too high.

- C. The migration measures may not be updated in a timely manner.
- D. The security program may not be aligned with organizational objectives.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 512

Following a risk assessment, new countermeasures have been approved by management. Which of the following should be performed NEXT?

- A. Schedule the target end date for implementation activities.
- B. Budget the total cost of implementation activities.
- C. Develop an implementation strategy.
- D. Calculate the residual risk for each countermeasure.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 513

Which of the following would be of GREATEST concern to an IS auditor evaluating governance over open source development components?

- A. The development project has gone over budget and time
- B. The open source development components do not meet industry best practices
- C. The software is not analyzed for compliance with organizational requirements
- D. Existing open source policies have not been approved in over a year

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 514

The PRIMARY objective of value delivery in reference to IT governance is to:

- A. increase efficiency
- B. promote best practices
- C. optimize investments
- D. ensure compliance

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 515

Which of the following is the PRIMARY objective of implementing IT governance?

- A. Resource management
- B. Performance measurement
- C. Value delivery
- D. Strategic planning

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 516

Which of the following is necessary for the effective risk management in IT governance?

- A. Risk evaluation is embedded in management processes
- B. Risk management strategy is approved by the audit committee
- C. Local managers are solely responsible for risk evaluation
- D. IT risk management is separate from corporate risk management

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 517

Which of the following should be an IS auditor's PRIMARY consideration when evaluating the development and design of a privacy program?

- A. Data governance and data classification procedures
- B. Policies and procedures consistent with privacy guidelines
- C. Industry practice and regulatory compliance guidance

D. Information security and incident management practices

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 518

Which of the following is the PRIMARY objective of implementing privacy-related controls within an organization?

- A. To identify data at rest and data in transit for encryption
- B. To prevent confidential data loss
- C. To comply with legal and regulatory requirements
- D. To provide options to individuals regarding use of their data

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 519

An IS audit of an organization's data classification policies finds some areas of the policies may not be up-to- date with new data privacy regulations. What should management do FIRST to address the risk of

noncompliance?

- A. Conduct a privacy impact assessment to identify gaps
- B. Reclassify information based on revised information classification labels
- C. Mandate training on the new privacy regulations
- D. Perform a data discovery exercise to identify all personal data

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 520

Which of the following is MOST important to consider when assessing the scope of privacy concerns for an IT project?

- A. Applicable laws and regulations
- B. End user access rights
- C. Business requirements
- D. Classification of data

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 521

Which of the following presents the GREATEST concern when implementing data flow across borders?

- A. Software piracy laws
- B. National privacy laws
- C. Political unrest
- D. Equipment incompatibilities

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 522

When an organization is having new software implemented under contract, which of the following is key to controlling escalating costs due to scope creep?

- A. Problem management
- B. Quality management
- C. Change management
- D. Risk management

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 523

Which of the following is the MOST important reason to use statistical sampling?

- A. The results are more defensible
- B. It ensures that all relevant cases are covered
- C. It reduces time required for testing

D. The results can reduce error rates

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 524

Which of the following is MOST critical to the success of an information security program?

- A. Integration of business and information security
- B. Alignment of information security with IT objectives
- C. Management's commitment to information security
- D. User accountability for information security

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 525

Which of the following is the MAIN purpose of data classification?

- A. Applying the appropriate protective measures
- B. Ensuring the segregation of duties
- C. Defining parameter requirements for security labels
- D. Ensuring integrity of sensitive information

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 526

The decision to accept an IT control risk related to data quality should be the responsibility of the:

- A. information security team
- B. chief information officer (CIO)
- C. business owner
- D. IS audit manager

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 527

Which of the following would be MOST time and cost efficient when performing a control self-assessment (CSA) for an organization with a large number of widely dispersed employees?

- A. Top-down and bottom-up analysis
- B. Face-to-face interviews
- C. Survey questionnaire
- D. Facilitated workshops

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 528

In attribute sampling, what is the relationship between expected error rate and sample size?

- A. The expected error rate does not affect the sample size
- B. The greater the expected error rate, the smaller the sample size
- C. The greater the expected error rate, the greater the sample size
- D. The greater the sample size, the lower the expected error rate

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 529

The MOST important reason why an IT risk assessment should be updated on a regular basis is to:

- A. utilize IT resources in a cost-effective manner
- B. comply with data classification changes
- C. comply with risk management policies
- D. react to changes in the IT environment

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 530

An IT governance framework provides an organization with:

- A. a basis for directing and controlling IT.
- B. assurance that there will be IT cost reductions.
- C. organizational structures to enlarge the market share through IT.
- D. assurance that there are surplus IT investments.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 531

Which of the following is a key success factor for implementing IT governance?

- A. Embedding quality assurance processes
- B. Establishing an IT governance committee
- C. Aligning IT and business strategies
- D. Delivering IT projects within budget

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 532

Which of the following groups is MOST likely responsible for the implementation of IT projects?

- A. IT steering committee
- B. IT compliance committee
- C. IT strategy committee
- D. IT governance committee

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 533

The chief information officer (CIO) of an organization is concerned that the information security policies may not be comprehensive. Which of the following should an IS auditor recommend be performed FIRST?

- A. Obtain a copy of their competitor's policies.
- B. Determine if there is a process to handle exceptions to the policies.
- C. Establish a governance board to track compliance with the policies.
- D. Compare the policies against an industry framework.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 534

An IS auditor can BEST help management fulfill risk management responsibilities by:

- A. highlighting specific risks not being addressed.
- B. ensuring the roles for managing IT risk are defined.
- C. developing an IT risk management framework.
- D. adopting a mechanism for reporting issues.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 535

Which of the following is the BEST source for describing the objectives of an organization's information systems?

- A. Business process owners
- B. End users
- C. IT management
- D. Information security management

Correct Answer: D
Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 536

Which of the following is the BEST way for management to ensure the effectiveness of the cybersecurity incident response process?

- A. Periodic update of incident response process documentation
- B. Periodic reporting of cybersecurity incidents to key stakeholders
- C. Periodic tabletop exercises involving key stakeholders
- D. Periodic cybersecurity training for staff involved in incident response

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 537

An organization was recently notified by its regulatory body of significant discrepancies in its reporting data. A preliminary investigation revealed that the discrepancies were caused by problems with the organization's data quality. Management has directed the data quality team to enhance their program. The audit committee has asked internal audit to be advisors to the process. To ensure that management concerns are addressed, which data set should internal audit recommend be reviewed FIRST?

- A. Data impacting business objectives
- B. Data supporting financial statements
- C. Data reported to the regulatory body
- D. Data with customer personal information

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 538

An IS auditor has been asked to advise on the design and implementation of IT management best practices. Which of the following actions would impair the auditor's independence?

- A. Providing consulting advice for managing applications
- B. Designing an embedded audit module
- C. Implementing risk response on management's behalf
- D. Evaluating the risk management process

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 539

Which of the following is the MOST effective means of helping management and the IT strategy committee to monitor IT performance?

- A. End-user satisfaction surveys
- B. Gap analysis
- C. Measurement of service levels against metrics
- D. Infrastructure monitoring reports

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 540

Management decided to accept the residual risk of an audit finding and not take the recommended actions. The internal audit team believes the acceptance is inappropriate and has discussed the situation with executive management. After this discussion, there is still disagreement regarding the decision. Which of the following is the BEST course of action by internal audit?

- A. Report this matter to the audit committee without notifying executive management.
- B. Document in the audit report that management has accepted the residual risk and take no further actions.
- C. Report the issue to the audit committee in a joint meeting with executive management for resolution.
- D. Schedule another meeting with executive management to convince them of taking action as recommended.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 541

An IS auditor has completed a service level management audit related to order management services provided by a third party. Which of the following is the MOST significant finding?

- A. The third party has offshore support arrangements.
- B. Penalties for missing service levels are limited.
- C. The service level agreement does not define how availability is measured.
- D. Service desk support is not available outside the company's business hours.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 542

To help ensure the accuracy and completeness of end-user computing output, it is MOST important to include strong:

- A. reconciliation controls.
- B. change management controls.
- C. access management controls.
- D. documentation controls.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 543

Spreadsheets are used to calculate project cost estimates. Totals for each cost category are then keyed into the job-costing system. What is the BEST control to ensure that data are accurately entered into the system?

- A. Reasonableness checks for each cost type
- B. Validity checks, preventing entry of character data
- C. Display back of project detail after entry
- D. Reconciliation of total amounts by project

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 544

Rather than decommission an entire legacy application, an organization's IT department has chosen to replace specific modules while maintaining those still relevant. Which of the following artifacts is MOST important for an IS auditor to review?

- A. IT service management catalog and service level requirements
- B. Security requirements for legacy data masking and data destruction
- C. Applicable licensing agreements for the application
- D. Future state architecture and requirements

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 545

During a network security review, the system log indicates an unusually high number of unsuccessful login attempts. Which of the following sampling techniques is MOST appropriate for selecting a sample of user IDs for further investigation?

- A. Stratified
- B. Attribute
- C. Monetary unit
- D. Variable

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 546

The PRIMARY role of a control self-assessment (CSA) facilitator is to:

- A. report on the internal control weaknesses.
- B. focus the team on internal controls.
- C. provide solutions for control weaknesses.
- D. conduct interviews to gain background information.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 547

Which of the following is the MOST important consideration for an organization when strategizing to comply with privacy regulations?

- A. Ensuring there are staff members with in-depth knowledge of the privacy regulations
- B. Ensuring up-to-date knowledge of where customer data is saved
- C. Ensuring regularly updated contracts with third parties that process customer data
- D. Ensuring appropriate access to information systems containing privacy information.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 548

Which of the following would be best suited to oversee the development of an information security policy?

- A. System Administrators
- B. End User
- C. Security Officers
- D. Security administrators

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

The security officer would be the best person to oversee the development of such policies.

Security officers and their teams have typically been charged with the responsibility of creating the security policies. The policies must be written and communicated appropriately to ensure that they can be understood by the end users. Policies that are poorly written, or written at too high of an education level (common industry practice is to focus the content for general users at the sixth- to eighth-grade reading level), will not be understood.

Implementing security policies and the items that support them shows due care by the company and its management staff. Informing employees of what is expected of them and the consequences of noncompliance can come down to a liability issue.

While security officers may be responsible for the development of the security policies, the effort should be collaborative to ensure that the business issues are addressed.

The security officers will get better corporate support by including other areas in policy development. This helps build buy-in by these areas as they take on a greater ownership of the final product. Consider including areas such as HR, legal, compliance, various IT areas and specific business area representatives who represent critical business units.

When policies are developed solely within the IT department and then distributed without business input, they are likely to miss important business considerations. Once policy documents have been created, the basis for ensuring compliance is established. Depending on the organization, additional documentation may be necessary to support policy. This support may come in the form of additional controls described in standards, baselines, or procedures to help personnel with compliance. An important step after documentation is to make

the most current version of the documents readily accessible to those who are expected to follow them. Many organizations place the documents on their intranets or in shared file folders to facilitate their accessibility. Such placement of these documents plus checklists, forms, and sample documents can make awareness more effective.

For your exam you should know the information below:

End User - The end user is responsible for protecting information assets on a daily basis through adherence to the security policies that have been communicated.

Executive Management/Senior Management -Executive management maintains the overall responsibility for protection of the information assets. The business operations are dependent upon information being available, accurate, and protected from individuals without a need to know.

Security Officer - The security officer directs, coordinates, plans, and organizes information security activities throughout the organization. The security officer works with many different individuals, such as executive management, management of the business units, technical staff, business partners, auditors, and third parties such as vendors. The security officer and his or her team are responsible for the design, implementation, management, and review of the organization's security policies, standards, procedures, baselines, and guidelines.

Information Systems Security Professional-Drafting of security policies, standards and supporting guidelines, procedures, and baselines is coordinated through these individuals. Guidance is provided for technical security issues, and emerging threats are considered for the adoption of new policies. Activities such as interpretation of government regulations and industry trends and analysis of vendor solutions to include in the security architecture that advances the security of the organization are performed in this role.

Data/Information/Business/System Owners - A business executive or manager is typically responsible for an information asset. These are the individuals that assign the appropriate classification to information assets. They ensure that the business information is protected with appropriate controls. Periodically, the information asset owners need to review the classification and access rights associated with information assets. The owners, or their delegates, may be required to approve access to the information. Owners also need to determine the criticality, sensitivity, retention, backups, and safeguards for the information. Owners or their delegates are responsible for understanding the risks that exist with regards to the information that they control.

Data/Information Custodian/Steward - A data custodian is an individual or function that takes care of the information on behalf of the owner. These individuals ensure that the information is available to the end users and is backed up to enable recovery in the event of data loss or corruption. Information may be stored in files, databases, or systems whose technical infrastructure must be managed, by systems administrators. This group administers access rights to the information assets.

Information Systems Auditor-IT auditors determine whether users, owners, custodians, systems, and networks are in compliance with the security policies, procedures, standards, baselines, designs, architectures, management direction, and other requirements placed on systems. The auditors provide independent assurance to the management on the appropriateness of the security controls. The auditor examines the information systems and determines whether they are designed, configured, implemented, operated, and managed in a way ensuring that the organizational objectives are being achieved. The auditors provide top company management with an independent view of the controls and their effectiveness.

Business Continuity Planner -Business continuity planners develop contingency plans to prepare for any occurrence that could have the ability to impact the company's objectives negatively. Threats may include earthquakes, tornadoes, hurricanes, blackouts, changes in the economic/political climate, terrorist activities, fire, or other major actions potentially causing significant harm. The business continuity planner ensures that business processes can continue through the disaster and coordinates those activities with the business areas and information technology personnel responsible for disaster recovery.

Information Systems/ Technology Professionals-These personnel are responsible for designing security controls into information systems, testing the controls, and implementing the systems in production

environments through agreed upon operating policies and procedures. The information systems professionals work with the business owners and the security professionals to ensure that the designed solution provides security controls commensurate with the acceptable criticality, sensitivity, and availability requirements of the application.

Security Administrator - A security administrator manages the user access request process and ensures that privileges are provided to those individuals who have been authorized for access by application/system/data owners. This individual has elevated privileges and creates and deletes accounts and access permissions. The security administrator also terminates access privileges when individuals leave their jobs or transfer between company divisions. The security administrator maintains records of access request approvals and produces reports of access rights for the auditor during testing in an access controls audit to demonstrate

compliance with the policies.

Network/Systems Administrator - A systems administrator (sysadmin/netadmin) configures network and server hardware and the operating systems to ensure that the information can be available and accessible. The administrator maintains the computing infrastructure using tools and utilities such as patch management and software distribution mechanisms to install updates and test patches on organization computers. The administrator tests and implements system upgrades to ensure the continued reliability of the servers and network devices. The administrator provides vulnerability management through either commercial off the shelf (COTS) and/or non-COTS solutions to test the computing environment and mitigate vulnerabilities appropriately.

Physical Security - The individuals assigned to the physical security role establish relationships with external law enforcement, such as the local police agencies, state police, or the Federal Bureau of Investigation (FBI) to assist in investigations. Physical security personnel manage the installation, maintenance, and ongoing operation of the closed circuit television (CCTV) surveillance systems, burglar alarm systems, and card reader access control systems. Guards are placed where necessary as a deterrent to unauthorized access and to provide safety for the company employees. Physical security personnel interface with systems security, human resources, facilities, and legal and business areas to ensure that the practices are integrated.

Security Analyst - The security analyst role works at a higher, more strategic level than the previously described roles and helps develop policies, standards, and guidelines, as well as set various baselines. Whereas the previous roles are "in the weeds" and focus on pieces and parts of the security program, a security analyst helps define the security program elements and follows through to ensure the elements are being carried out and practiced properly. This person works more at a design level than at an implementation level.

Administrative Assistants/Secretaries - This role can be very important to information security; in many companies of smaller size, this may be the individual who greets visitors, signs packages in and out, recognizes individuals who desire to enter the offices, and serves as the phone screener for executives. These individuals may be subject to social engineering attacks, whereby the potential intruder attempts to solicit confidential information that may be used for a subsequent attack. Social engineers prey on the goodwill of the helpful individual to gain entry. A properly trained assistant will minimize the risk of divulging useful company information or of providing unauthorized entry.

Help Desk Administrator - As the name implies, the help desk is there to field questions from users that report system problems. Problems may include poor response time, potential virus infections, unauthorized access, inability to access system resources, or questions on the use of a program. The help desk is also often where the first indications of security issues and incidents will be seen. A help desk individual would contact the computer security incident response team (CIRT) when a situation meets the criteria developed by the team. The help desk resets passwords, resynchronizes/reinitializes tokens and smart cards, and resolves other problems with access control.

Supervisor - The supervisor role, also called user manager, is ultimately responsible for all user activity and any assets created and owned by these users. For example, suppose Kathy is the supervisor of ten employees. Her responsibilities would include ensuring that these employees understand their responsibilities with respect to security; making sure the employees' account information is up-to-date; and informing the security administrator when an employee is fired, suspended, or transferred. Any change that pertains to an employee's role within the company usually affects what access rights they should and should not have, so the

user manager must inform the security administrator of these changes immediately.

Change Control Analyst Since the only thing that is constant is change, someone must make sure changes happen securely. The change control analyst is responsible for approving or rejecting requests to make changes to the network, systems, or software. This role must make certain that the change will not introduce any vulnerabilities, that it has been properly tested, and that it is properly rolled out. The change control analyst needs to understand how various changes can affect security, interoperability, performance, and productivity. Or, a company can choose to just roll out the change and see what happens.

The following answers are incorrect:

Systems Administrator - A systems administrator (sysadmin/ netadmin) configures network and server hardware and the operating systems to ensure that the information can be available and accessible. The administrator maintains the computing infrastructure using tools and utilities such as patch management and software distribution mechanisms to install updates and test patches on organization computers. The administrator tests and implements system upgrades to ensure the continued reliability of the servers and network devices. The administrator provides vulnerability management through either commercial off the shelf (COTS) and/or non-COTS solutions to test the computing environment and mitigate vulnerabilities appropriately.

End User - The end user is responsible for protecting information assets on a daily basis through adherence to the security policies that have been communicated.

Security Administrator - A security administrator manages the user access request process and ensures that privileges are provided to those individuals who have been authorized for access by application/system/data owners. This individual has elevated privileges and creates and deletes accounts and access permissions. The security administrator also terminates access privileges when individuals leave their jobs or transfer between company divisions. The security administrator maintains records of access request approvals and produces reports of access rights for the auditor during testing in an access controls audit to demonstrate compliance with the policies.

CISA review manual 2014-10 Page number 109

Harris, Shun (2012-2018). CISSP All-in-One Exam Guide, 6th Edition (p. 108). McGraw-Hill. Kindle Edition.

QUESTION 549

Which of the following is the MOST important aspect relating to employee termination?

- A. The details of employee have been removed from active payroll files.
- B. Company property provided to the employee has been returned.
- C. User ID and passwords of the employee have been deleted.
- D. The appropriate company staff are notified about the termination.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

Even though Logical access to information by a terminated employee is possible if the ID and password of the terminated employee has not been deleted this is only one part of the termination procedures. If user ID is not disabled or deleted, it could be possible for the employee without physical access to visit the company's networks remotely and gain access to the information.

Please note that this can also be seen in a different way: the most important thing to do could also be to inform others of the person's termination, because even if user ID's and passwords are deleted, a terminated individual could simply socially engineer their way back in by calling an individual he/she used to work with and ask them for access. He could intrude on the facility or use other weaknesses to gain access to information

after he has been terminated.

By notifying the appropriate company staff about the termination, they would in turn initiate account termination, ask the employee to return company property, and all credentials would be withdrawn for the individual concerned. This answer is more complete than simply disabling account.

It seems harsh and cold when this actually takes place, but too many companies have been hurt by vengeful employees who have lashed out at the company when their positions were revoked for one reason or another. If an employee is disgruntled in any way, or the termination is unfriendly, that employee's accounts should be disabled right away, and all passwords on all systems changed.

For your exam you should know the information below:

Employee Termination Processes

Employees join and leave organizations every day. The reasons vary widely, due to retirement, reduction in force, layoffs, termination with or without cause,

relocation to another city, career opportunities with other employers, or involuntary transfers. Terminations may be friendly or unfriendly and will need different levels of care as a result.

Friendly Terminations

Regular termination is when there is little or no evidence or reason to believe that the termination is not agreeable to both the company and the employee. A standard set of procedures, typically maintained by the human resources department, governs the dismissal of the terminated employee to ensure that company property is returned, and all access is removed. These procedures may include exit interviews and return of keys, identification cards, badges, tokens, and cryptographic keys. Other property, such as laptops, cable locks, credit cards, and phone cards, are also collected. The user manager notifies the security department of the termination to ensure that access is revoked for all platforms and facilities. Some facilities choose to immediately delete the accounts, while others choose to disable the accounts for a policy defined period, for example, 30 days, to account for changes or extensions in the final termination date. The termination process should include a conversation with the departing associate about their continued responsibility for confidentiality of information.

Unfriendly Terminations

Unfriendly terminations may occur when the individual is fired, involuntarily transferred, laid off, or when the organization has reason to believe that the individual has the means and intention to potentially cause harm to the system. Individuals with technical skills and higher levels of access, such as the systems administrators, computer programmers, database administrators, or any individual with elevated privileges, may present higher risk to the environment. These individuals could alter files, plant logic bombs to create system file damage at a future date, or remove sensitive information. Other disgruntled users could enter erroneous data into the system that may not be discovered for several months. In these situations, immediate termination of systems access is warranted at the time of termination or prior to notifying the employee of the termination. Managing the people aspect of security, from pre-employment to postemployment, is critical to ensure that trustworthy, competent resources are employed to further the business objectives that will protect company information. Each of these actions contributes to preventive, detective, or corrective personnel controls.

The following answers are incorrect:

The other options are less important.

CISA review manual 2014 Page number 99

Harris, Shun (2012-10-18). CISSP All-in-One Exam Guide, 6th Edition (p. 129). McGraw-Hill. Kindle Edition.

QUESTION 550

In which of the following cloud computing service model are applications hosted by the service provider and made available to the customers over a network?

- A. Software as a service
- B. Data as a service
- C. Platform as a service
- D. Infrastructure as a service

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

Software as a Service (SaaS) is a software distribution model in which applications are hosted by a vendor or service provider and made available to customers over a network, typically the Internet. SaaS is closely related to the ASP (application service provider) and on demand computing software delivery models.

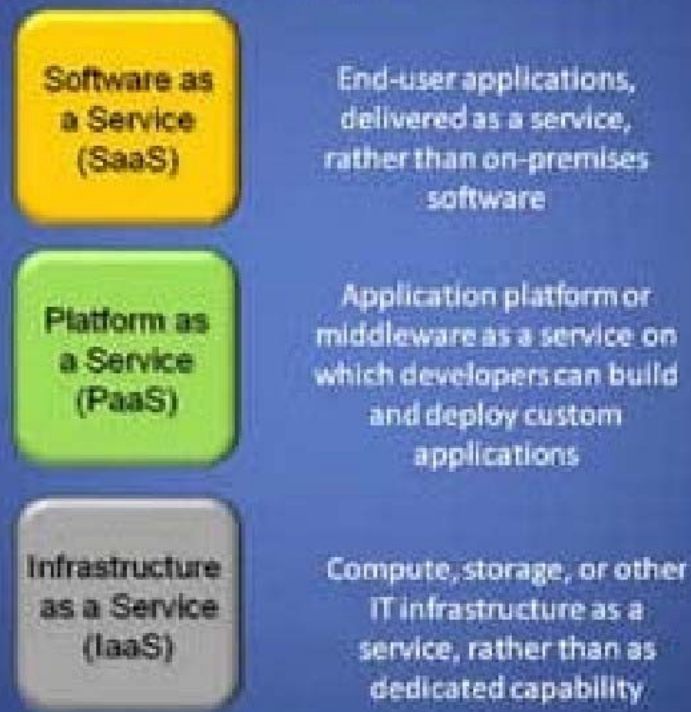
For your exam you should know below information about Cloud Computing:

Cloud computing is a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. This cloud model promotes availability and is composed of five essential characteristics, three service models, and four deployment models.

Cloud computing service model

Cloud computing service models

Cloud Computing Service Models



Software as a Service (SaaS)

Software as a Service (SaaS) is a software distribution model in which applications are hosted by a vendor or service provider and made available to customers over a network, typically the Internet. SaaS is closely related to the ASP (application service provider) and on demand computing software delivery models. IDC identifies two slightly different delivery models for SaaS. The hosted application management (hosted AM) model is similar to ASP: a provider hosts commercially available software for customers and delivers it over the Web. In the software on demand model, the provider gives customers network-based access to a single copy of an application created specifically for SaaS distribution.

Provider gives users access to specific application software (CRM, e-mail, games). The provider gives the customers network based access to a single copy of an application created specifically for SaaS distribution

and use.

Benefits of the SaaS model include:

- easier administration
- automatic updates and patch management
- compatibility: All users will have the same version of software.
- easier collaboration, for the same reason
- global accessibility.

Platform as a Service (PaaS)

Platform as a Service (PaaS) is a way to rent hardware, operating systems, storage and network capacity over the Internet. The service delivery model allows the customer to rent virtualized servers and associated services for running existing applications or developing and testing new ones.

Cloud providers deliver a computing platform, which can include an operating system, database, and web server as a holistic execution environment. Where IaaS is the "raw IT network," PaaS is the software environment that runs on top of the IT network.

Platform as a Service (PaaS) is an outgrowth of Software as a Service (SaaS), a software distribution model in which hosted software applications are made available to customers over the Internet. PaaS has several advantages for developers. With PaaS, operating system features can be changed and upgraded frequently. Geographically distributed development teams can work together on software development projects. Services can be obtained from diverse sources that cross international boundaries. Initial and ongoing costs can be reduced by the use of infrastructure services from a single vendor rather than maintaining multiple hardware facilities that often perform duplicate functions or suffer from incompatibility problems. Overall expenses can also be minimized by unification of programming development efforts.

On the downside, PaaS involves some risk of "lock-in" if offerings require proprietary service interfaces or development languages. Another potential pitfall is that the flexibility of offerings may not meet the needs of some users whose requirements rapidly evolve.

Infrastructure as a Service (IaaS)

Cloud providers offer the infrastructure environment of a traditional data center in an on-demand delivery method. Companies deploy their own operating systems, applications, and software onto this provided infrastructure and are responsible for maintaining them.

Infrastructure as a Service is a provision model in which an organization outsources the equipment used to support operations, including storage, hardware, servers and networking components. The service provider owns the equipment and is responsible for housing, running and maintaining it. The client typically pays

on a per-use basis.

The following answers are incorrect:

Data as a service - Data Provided as a service rather than needing to be loaded and prepared on premises. Platform as a service - Platform as a Service (Peas) is a way to rent hardware, operating systems, storage and network capacity over the Internet. The service delivery model allows the customer to rent virtualized servers and associated services for running existing applications or developing and testing new ones. Infrastructure as a service - Infrastructure as a Service is a provision model in which an organization outsources the equipment used to support operations, including storage, hardware, servers and networking components. The service provider owns the equipment and is responsible for housing, running and maintaining it. The client typically pays on a per-use basis.

CISA review manual 2014 page number 102

Official ISC2 guide to CISSP 3rd edition Page number 689

<http://searchcloudcomputing.techtarget.com/definition/Software-as-a-Service> <http://searchcloudcomputing.techtarget.com/definition/Platform-as-a-Service-PaaS>

<http://searchcloudcomputing.techtarget.com/definition/Infrastructure-as-a-Service-IaaS>

QUESTION 551

Which of the following cloud computing service model provides a way to rent operating systems, storage and network capacity over the Internet?

- A. Software as a service
- B. Data as a service
- C. Platform as a service
- D. Infrastructure as a service

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

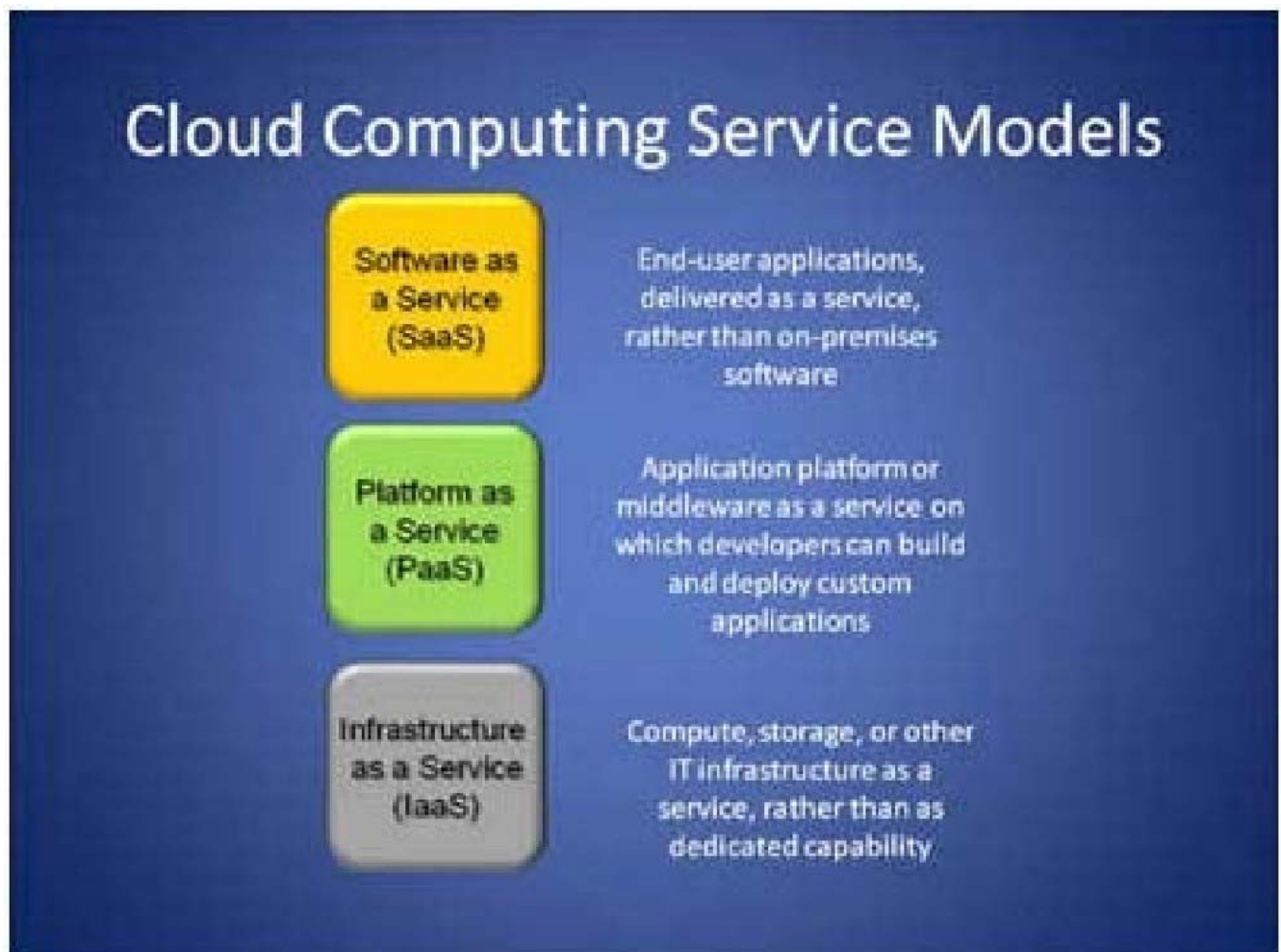
Platform as a Service (Peas) is a way to rent operating systems, storage and network capacity over the Internet. The service delivery model allows the customer to rent virtualized servers and associated services for running existing applications or developing and testing new ones. For your exam you should know below information about Cloud Computing:

Cloud computing is a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. This cloud model promotes availability and is composed of five essential characteristics, three service models, and four deployment models.

Cloud Computing

Cloud computing service models:

Cloud computing service models



Software as a Service (Seas)

Software as a Service (Seas) is a software distribution model in which applications are hosted by a vendor or

service provider and made available to customers over a network, typically the Internet. SaaS is closely related to the ASP (application service provider) and on demand computing software delivery models. IDC identifies two slightly different delivery models for Seas. The hosted application management (hosted AM) model is similar to ASP: a provider hosts commercially available software for customers and delivers it over the Web. In the software on demand model, the provider gives customers network-based access to a single copy of an application created specifically for Seas distribution.

Provider gives users access to specific application software (CRM, e-mail, games). The provider gives the customers network based access to a single copy of an application created specifically for Seas distribution and use.

Benefits of the Seas model include:

easier administration
automatic updates and patch management
compatibility: All users will have the same version of software.
easier collaboration, for the same reason
global accessibility.

Platform as a Service (Peas)

Platform as a Service (Peas) is a way to rent operating systems, storage and network capacity over the Internet. The service delivery model allows the customer to rent virtualized servers and associated services for running existing applications or developing and testing new ones.

Cloud providers deliver a computing platform, which can include an operating system, database, and web server as a holistic execution environment. Where IaaS is the "raw IT network," Peas is the software environment that runs on top of the IT network.

Platform as a Service (Peas) is an outgrowth of Software as a Service (SaaS), a software distribution model in which hosted software applications are made available to customers over the Internet. Peas has several advantages for developers. With Peas, operating system features can be changed and upgraded frequently. Geographically distributed development teams can work together on software development projects. Services can be obtained from diverse sources that cross international boundaries. Initial and ongoing costs can be reduced by the use of infrastructure services from a single vendor rather than maintaining multiple hardware facilities that often perform duplicate functions or suffer from incompatibility problems. Overall expenses can also be minimized by unification of programming development efforts.

On the downside, Peas involves some risk of "lock-in" if offerings require proprietary service interfaces or development languages. Another potential pitfall is that the flexibility of offerings may not meet the needs of some users whose requirements rapidly evolve.

Infrastructure as a Service (IaaS)

Cloud providers offer the infrastructure environment of a traditional data center in an on-demand delivery method. Companies deploy their own operating systems, applications, and software onto this provided infrastructure and are responsible for maintaining them.

Infrastructure as a Service is a provision model in which an organization outsources the equipment used to support operations, including storage, hardware, servers and networking components. The service provider owns the equipment and is responsible for housing, running and maintaining it. The client typically pays on a per-use basis.

Characteristics and components of IaaS include:

Utility computing service and billing model.
Automation of administrative tasks.
Dynamic scaling.
Desktop virtualization.
Policy-based services.
Internet connectivity.

Infrastructure as a Service is sometimes referred to as Hardware as a Service (HaaS).

The following answers are incorrect:

Data as a service - Data Provided as a service rather than needing to be loaded and prepared on premises.

Software as a service - Software as a Service (SaaS) is a software distribution model in which applications are hosted by a vendor or service provider and made available to customers over a network, typically the Internet. SaaS is closely related to the ASP (application service provider) and on demand computing software delivery models.

Infrastructure as a service - Infrastructure as a Service is a provision model in which an organization outsources the equipment used to support operations, including storage, hardware, servers and networking components. The service provider owns the equipment and is responsible for housing, running and maintaining it. The client typically pays on a per-use basis.

CISA review manual 2014 page number 102

Official ISC2 guide to CISSP 3rd edition Page number 689

<http://searchcloudcomputing.techtarget.com/definition/Software-as-a-Service> <http://searchcloudcomputing.techtarget.com/definition/Platform-as-a-Service-PaaS>

<http://searchcloudcomputing.techtarget.com/definition/Infrastructure-as-a-Service-IaaS>

QUESTION 552

Which of the following cloud computing service model is a provision model in which an organization outsources the equipment used to support operations, including storage, hardware, servers and networking components?

- A. Software as a service
- B. Data as a service
- C. Platform as a service
- D. Infrastructure as a service

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

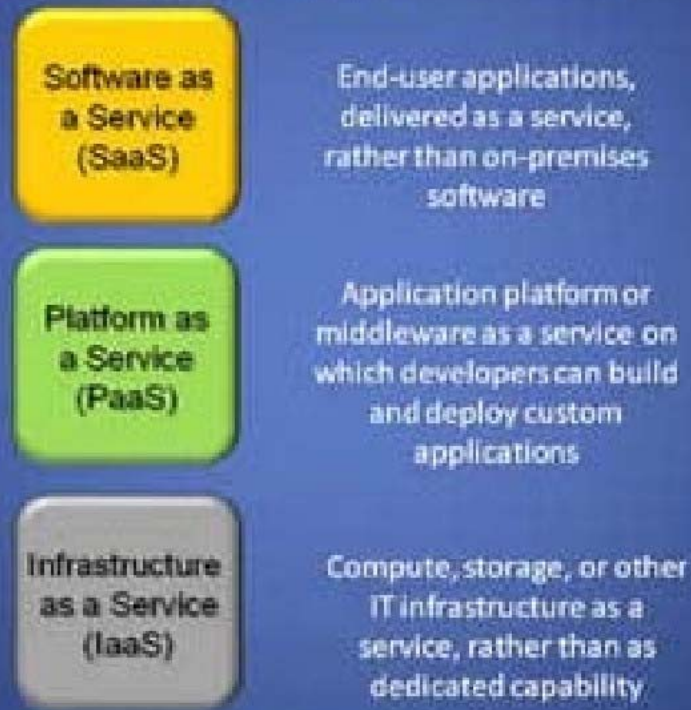
Infrastructure as a Service is a provision model in which an organization outsources the equipment used to support operations, including storage, hardware, servers and networking components. The service provider owns the equipment and is responsible for housing, running and maintaining it. The client typically pays on a per-use basis.

For your exam you should know below information about Cloud Computing:

Cloud computing is a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. This cloud model promotes availability and is composed of five essential characteristics, three service models, and four deployment models.

Cloud Computing

Cloud Computing Service Models



Cloud computing service models:

Cloud computing service models

Software as a Service (SaaS)

Software as a Service (SaaS) is a software distribution model in which applications are hosted by a vendor or service provider and made available to customers over a network, typically the Internet. SaaS is closely related to the ASP (application service provider) and on demand computing software delivery models. IDC identifies two slightly different delivery models for SaaS. The hosted application management (hosted AM) model is similar to ASP: a provider hosts commercially available software for customers and delivers it over the Web. In the software on demand model, the provider gives customers network-based access to a single copy of an application created specifically for SaaS distribution.

Provider gives users access to specific application software (CRM, e-mail, games). The provider gives the customers network based access to a single copy of an application created specifically for SaaS distribution and use.

Benefits of the SaaS model include:

easier administration

automatic updates and patch management

compatibility: All users will have the same version of software.

easier collaboration, for the same reason

global accessibility.

Platform as a Service (PaaS)

Platform as a Service (PaaS) is a way to rent hardware, operating systems, storage and network capacity over the Internet. The service delivery model allows the customer to rent virtualized servers and associated services for running existing applications or developing and testing new ones.

Cloud providers deliver a computing platform, which can include an operating system, database, and web server as a holistic execution environment. Where IaaS is the "raw IT network," PaaS is the software environment that runs on top of the IT network.

Platform as a Service (PaaS) is an outgrowth of Software as a Service (SaaS), a software distribution model in which hosted software applications are made available to customers over the Internet. PaaS has several advantages for developers. With PaaS, operating system features can be changed and upgraded frequently. Geographically distributed development teams can work together on software development projects. Services can be obtained from diverse sources that cross international boundaries. Initial and ongoing costs can be reduced by the use of infrastructure services from a single vendor rather than maintaining multiple hardware

facilities that often perform duplicate functions or suffer from incompatibility problems. Overall expenses can also be minimized by unification of programming development efforts.

On the downside, PaaS involves some risk of "lock-in" if offerings require proprietary service interfaces or development languages. Another potential pitfall is that the flexibility of offerings may not meet the needs of some users whose requirements rapidly evolve.

Infrastructure as a Service (IaaS)

Cloud providers offer the infrastructure environment of a traditional data center in an on-demand delivery method. Companies deploy their own operating systems, applications, and software onto this provided infrastructure and are responsible for maintaining them.

Infrastructure as a Service is a provision model in which an organization outsources the equipment used to support operations, including storage, hardware, servers and networking components. The service provider owns the equipment and is responsible for housing, running and maintaining it. The client typically pays on a per-use basis.

Characteristics and components of IaaS include:

Utility computing service and billing model.
Automation of administrative tasks.
Dynamic scaling.
Desktop virtualization.
Policy-based services.
Internet connectivity.

Infrastructure as a Service is sometimes referred to as Hardware as a Service (HaaS).

The following answers are incorrect:

Data as a service - Data Provided as a service rather than needing to be loaded and prepared on premises.

Software as a service - Software as a Service (SaaS) is a software distribution model in which applications are hosted by a vendor or service provider and made available to customers over a network, typically the Internet. SaaS is closely related to the ASP (application service provider) and on demand computing software delivery models.

Platform as a service - Platform as a Service (PaaS) is a way to rent hardware, operating systems, storage and network capacity over the Internet. The service delivery model allows the customer to rent virtualized servers and associated services for running existing applications or developing and testing new ones.

CISA review manual 2014 page number 102

Official ISC2 guide to CISSP 3rd edition Page number 689

<http://searchcloudcomputing.techtarget.com/definition/Software-as-a-Service> <http://searchcloudcomputing.techtarget.com/definition/Platform-as-a-Service-PaaS>

<http://searchcloudcomputing.techtarget.com/definition/Infrastructure-as-a-Service-IaaS>

QUESTION 553

Which of the following cloud deployment model operates solely for an organization?

- A. Private Cloud
- B. Community Cloud
- C. Public Cloud
- D. Hybrid Cloud

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

In Private cloud, the cloud infrastructure is provisioned for exclusive use by a single organization comprising multiple consumers (e.g., business units). It may be owned, managed, and operated by the organization, a third party, or some combination of them, and it may exist on or off premises.

For your exam you should know below information about Cloud Computing deployment models:

Private cloud

The cloud infrastructure is provisioned for exclusive use by a single organization comprising multiple consumers (e.g., business units). It may be owned, managed, and operated by the organization, a third party, or some combination of them, and it may exist on or off premises.

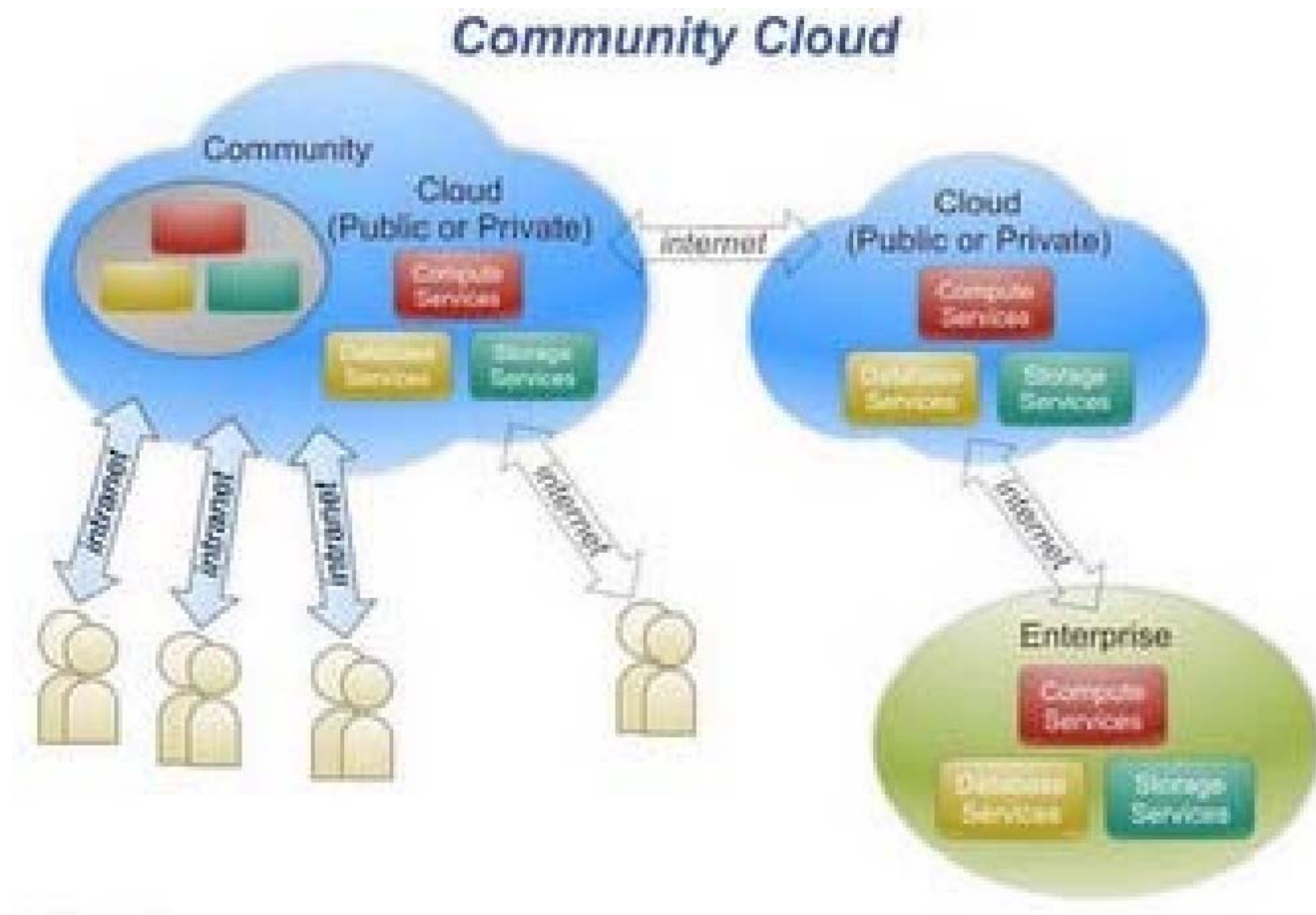
Private Cloud



Community Cloud

The cloud infrastructure is provisioned for exclusive use by a specific community of consumers from organizations that have shared concerns (e.g., mission, security requirements, policy, and compliance considerations). It may be owned, managed, and operated by one or more of the organizations in the community, a third party, or some combination of them, and it may exist on or off premises.

Community Cloud



Public Cloud

The cloud infrastructure is provisioned for open use by the general public. It may be owned, managed, and operated by a business, academic, or government organization, or some combination of them. It exists on the premises of the cloud provider.

Public Cloud



Hybrid cloud

The cloud infrastructure is a composition of two or more distinct cloud infrastructures (private, community, or public) that remain unique entities, but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds) hybrid cloud

The following answers are incorrect:

Community cloud - The cloud infrastructure is provisioned for exclusive use by a specific community of consumers from organizations that have shared concerns (e.g., mission, security requirements, policy, and compliance considerations). It may be owned, managed, and operated by one or more of the organizations in the community, a third party, or some combination of them, and it may exist on or off premises.

Public cloud - The cloud infrastructure is provisioned for open use by the general public. It may be owned, managed, and operated by a business, academic, or government organization, or some combination of them. It exists on the premises of the cloud provider.

Hybrid cloud - The cloud infrastructure is a composition of two or more distinct cloud infrastructures (private, community, or public) that remain unique entities, but are bound together by standardized or proprietary

technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds)

CISA review manual 2014 page number 102

Official ISC2 guide to CISSP 3rd edition Page number 689 and 690

QUESTION 554

Which of the following cloud deployment model can be shared by several organizations?

- A. Private Cloud\
- B. Community Cloud
- C. Public Cloud
- D. Hybrid Cloud

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

In Community cloud, the cloud infrastructure is provisioned for exclusive use by a specific community of consumers from organizations that have shared concerns (e.g., mission, security requirements, policy, and compliance considerations). It may be owned, managed, and operated by one or more of the organizations in the community, a third party, or some combination of them, and it may exist on or off premises.

For your exam you should know below information about Cloud Computing deployment models:

Private cloud

The cloud infrastructure is provisioned for exclusive use by a single organization comprising multiple consumers (e.g., business units). It may be owned, managed, and operated by the organization, a third party, or some combination of them, and it may exist on or off premises.

Private Cloud



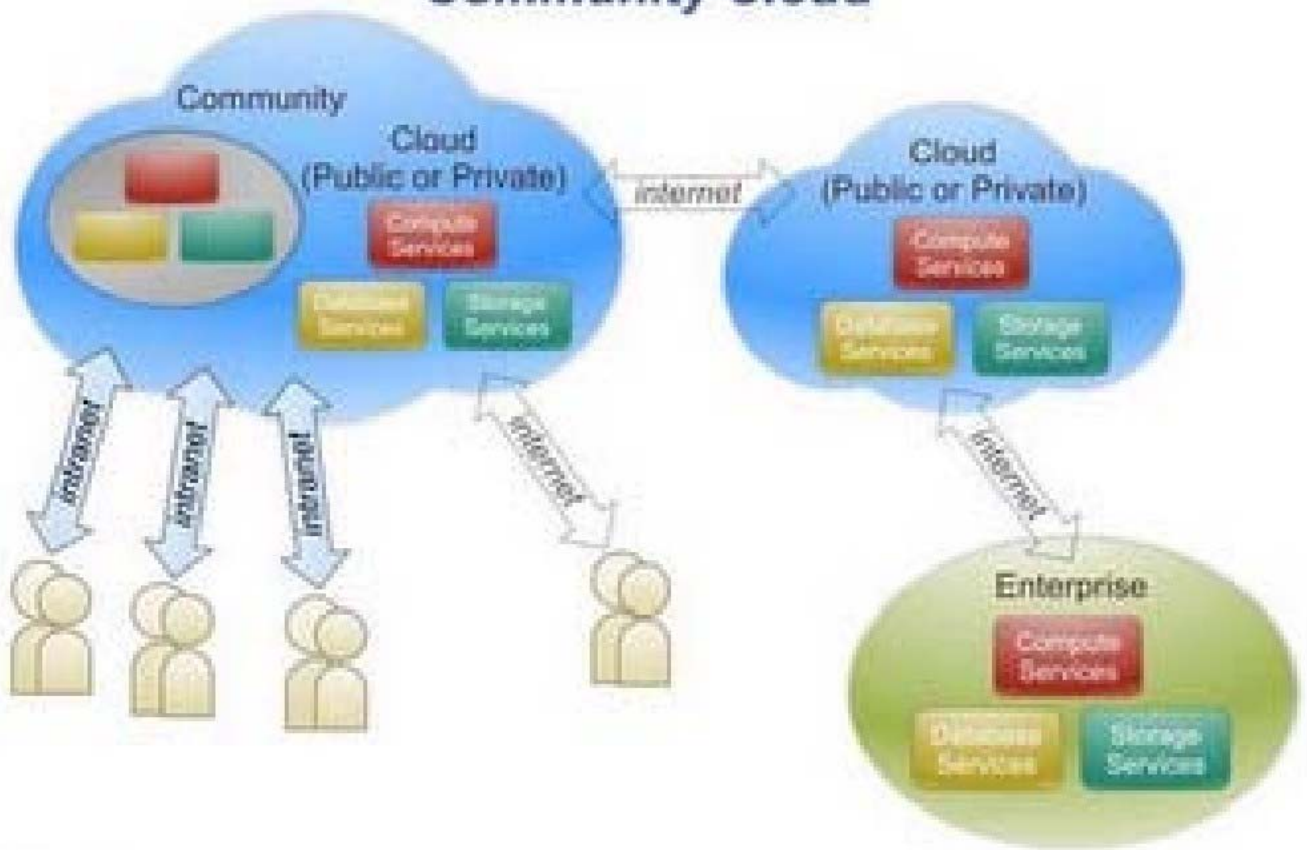
Community Cloud

The cloud infrastructure is provisioned for exclusive use by a specific community of consumers from organizations that have shared concerns (e.g., mission, security requirements, policy, and compliance considerations). It may be owned, managed, and operated by one or more of the organizations in the

community, a third party, or some combination of them, and it may exist on or off premises.

Community Cloud

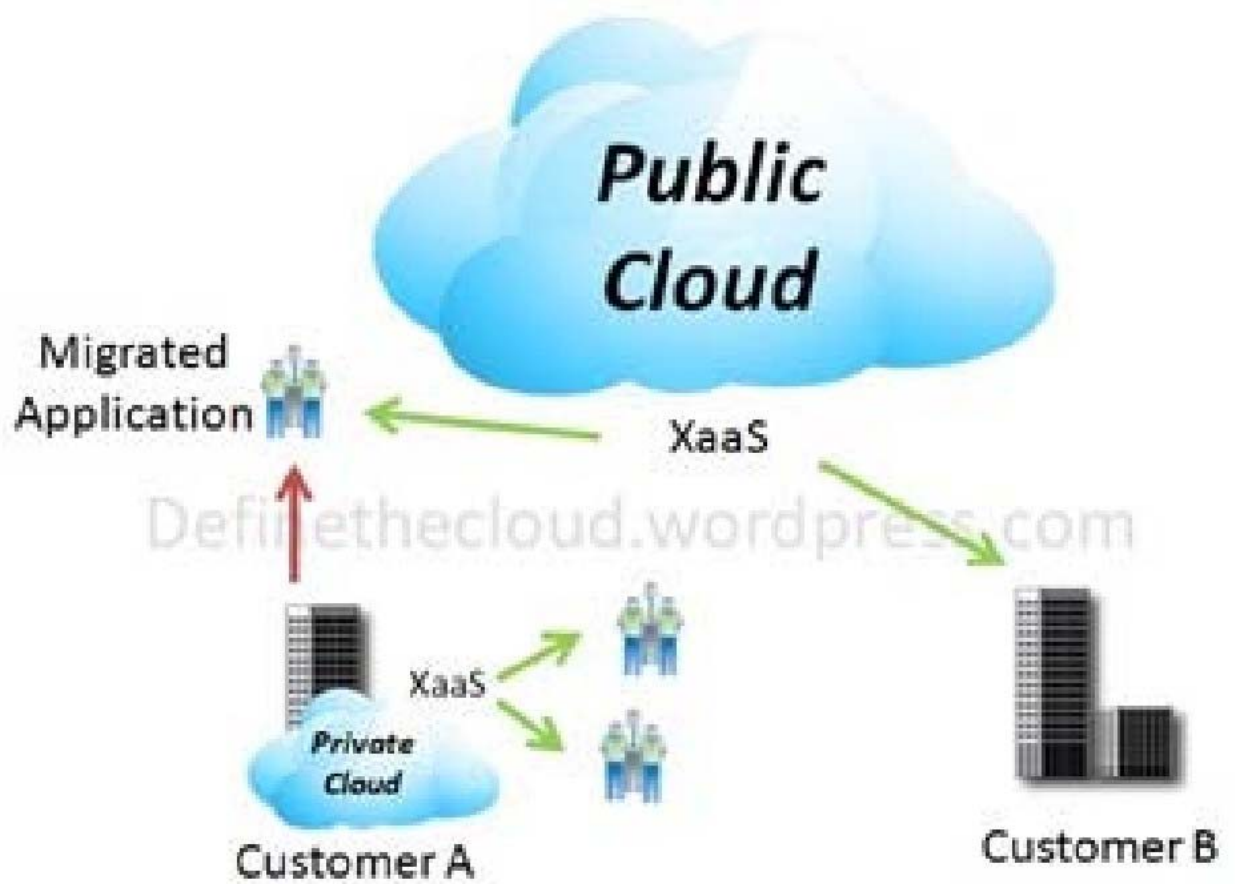
Community Cloud



Public Cloud

The cloud infrastructure is provisioned for open use by the general public. It may be owned, managed, and operated by a business, academic, or government organization, or some combination of them. It exists on the premises of the cloud provider.

Public Cloud



Hybrid cloud

The cloud infrastructure is a composition of two or more distinct cloud infrastructures (private, community, or public) that remain unique entities, but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds) hybrid cloud



The following answers are incorrect:

Private cloud - The cloud infrastructure is provisioned for exclusive use by a single organization comprising multiple consumers (e.g., business units). It may be owned, managed, and operated by the organization, a third party, or some combination of them, and it may exist on or off premises.

Public cloud - The cloud infrastructure is provisioned for open use by the general public. It may be owned, managed, and operated by a business, academic, or government organization, or some combination of them. It exists on the premises of the cloud provider.

Hybrid cloud - The cloud infrastructure is a composition of two or more distinct cloud infrastructures (private, community, or public) that remain unique entities, but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds)
CISA review manual 2014 page number 102
Official ISC2 guide to CISSP 3rd edition Page number 689 and 690

QUESTION 555

Which of the following cloud deployment model is provisioned for open use by the general public?

- A. Private Cloud
- B. Community Cloud
- C. Public Cloud
- D. Hybrid Cloud

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

In Public cloud, the cloud infrastructure is provisioned for open use by the general public. It may be owned, managed, and operated by a business, academic, or government organization, or some combination of them. It exists on the premises of the cloud provider.

For your exam you should know below information about Cloud Computing deployment models:

Private cloud

The cloud infrastructure is provisioned for exclusive use by a single organization comprising multiple consumers (e.g., business units). It may be owned, managed, and operated by the organization, a third party, or some combination of them, and it may exist on or off premises.

Private Cloud

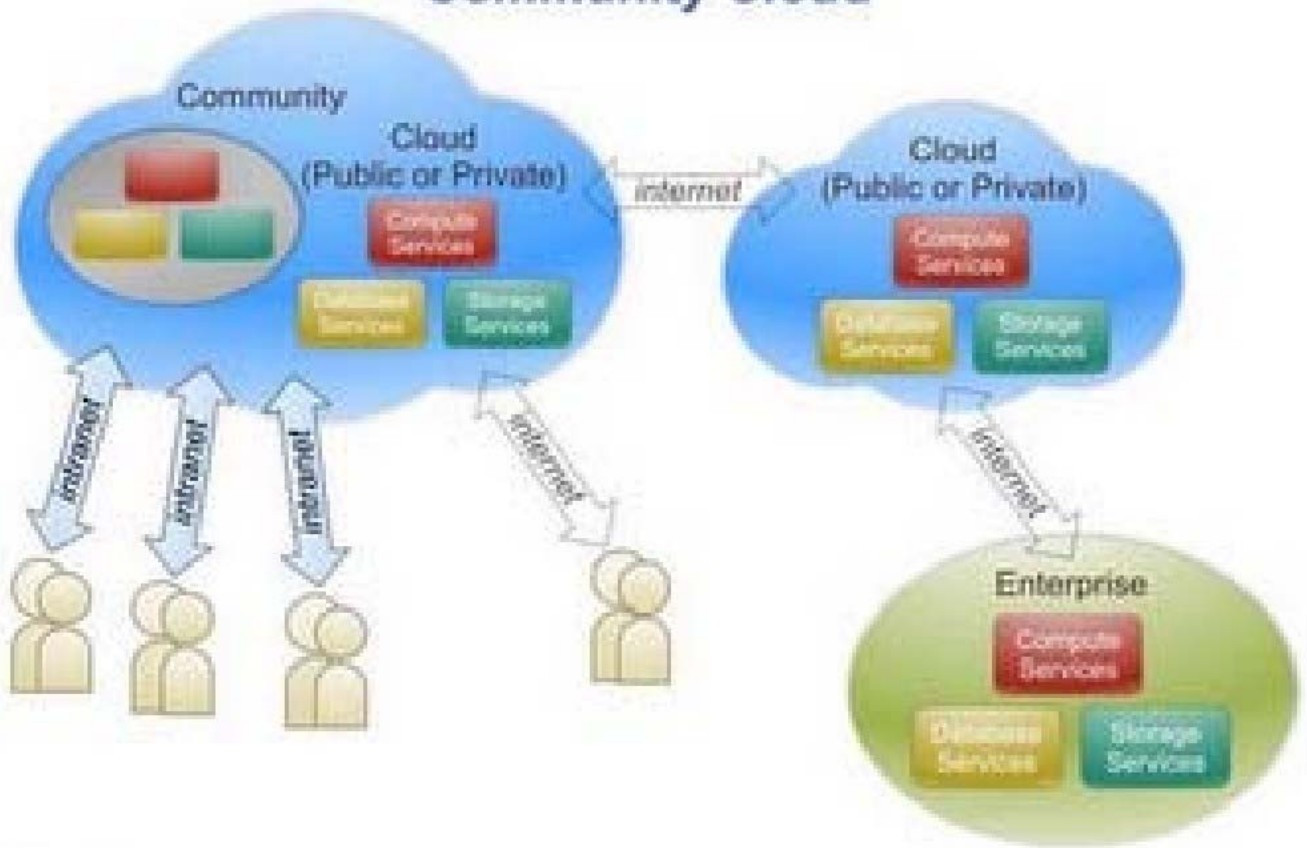


Community Cloud

The cloud infrastructure is provisioned for exclusive use by a specific community of consumers from organizations that have shared concerns (e.g., mission, security requirements, policy, and compliance considerations). It may be owned, managed, and operated by one or more of the organizations in the community, a third party, or some combination of them, and it may exist on or off premises.

Community Cloud

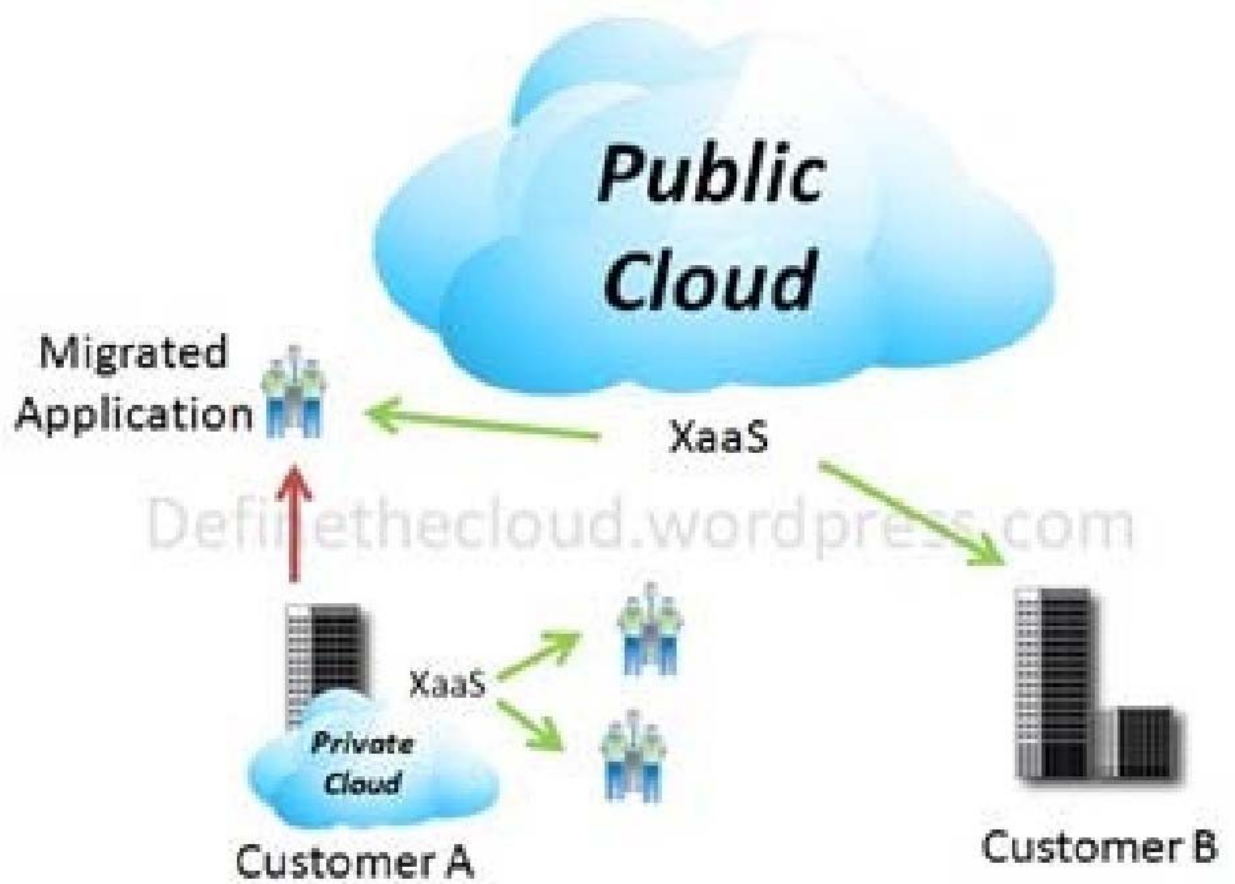
Community Cloud



Public Cloud

The cloud infrastructure is provisioned for open use by the general public. It may be owned, managed, and operated by a business, academic, or government organization, or some combination of them. It exists on the premises of the cloud provider.

Public Cloud



Hybrid cloud

The cloud infrastructure is a composition of two or more distinct cloud infrastructures (private, community, or public) that remain unique entities, but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds) hybrid cloud



The following answers are incorrect:

Private cloud - The cloud infrastructure is provisioned for exclusive use by a single organization comprising multiple consumers (e.g., business units). It may be owned, managed, and operated by the organization, a third party, or some combination of them, and it may exist on or off premises.

Community cloud - The cloud infrastructure is provisioned for exclusive use by a specific community of consumers from organizations that have shared concerns (e.g., mission, security requirements, policy, and compliance considerations). It may be owned, managed, and operated by one or more of the organizations in the community, a third party, or some combination of them, and it may exist on or off premises.

Hybrid cloud - The cloud infrastructure is a composition of two or more distinct cloud infrastructures (private, community, or public) that remain unique entities, but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds)
CISA review manual 2014 page number 102
Official ISC2 guide to CISSP 3rd edition Page number 689 and 690

QUESTION 556

Which of the following cloud deployment model is formed by the composition of two or more cloud deployment mode?

- A. Private Cloud
- B. Community Cloud
- C. Public Cloud
- D. Hybrid Cloud

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

In Hybrid cloud, the cloud infrastructure is a composition of two or more distinct cloud infrastructures (private, community, or public) that remain unique entities, but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds)

For your exam you should know below information about Cloud Computing deployment models:

Private cloud

The cloud infrastructure is provisioned for exclusive use by a single organization comprising multiple consumers (e.g., business units). It may be owned, managed, and operated by the organization, a third party, or some combination of them, and it may exist on or off premises.

Private Cloud

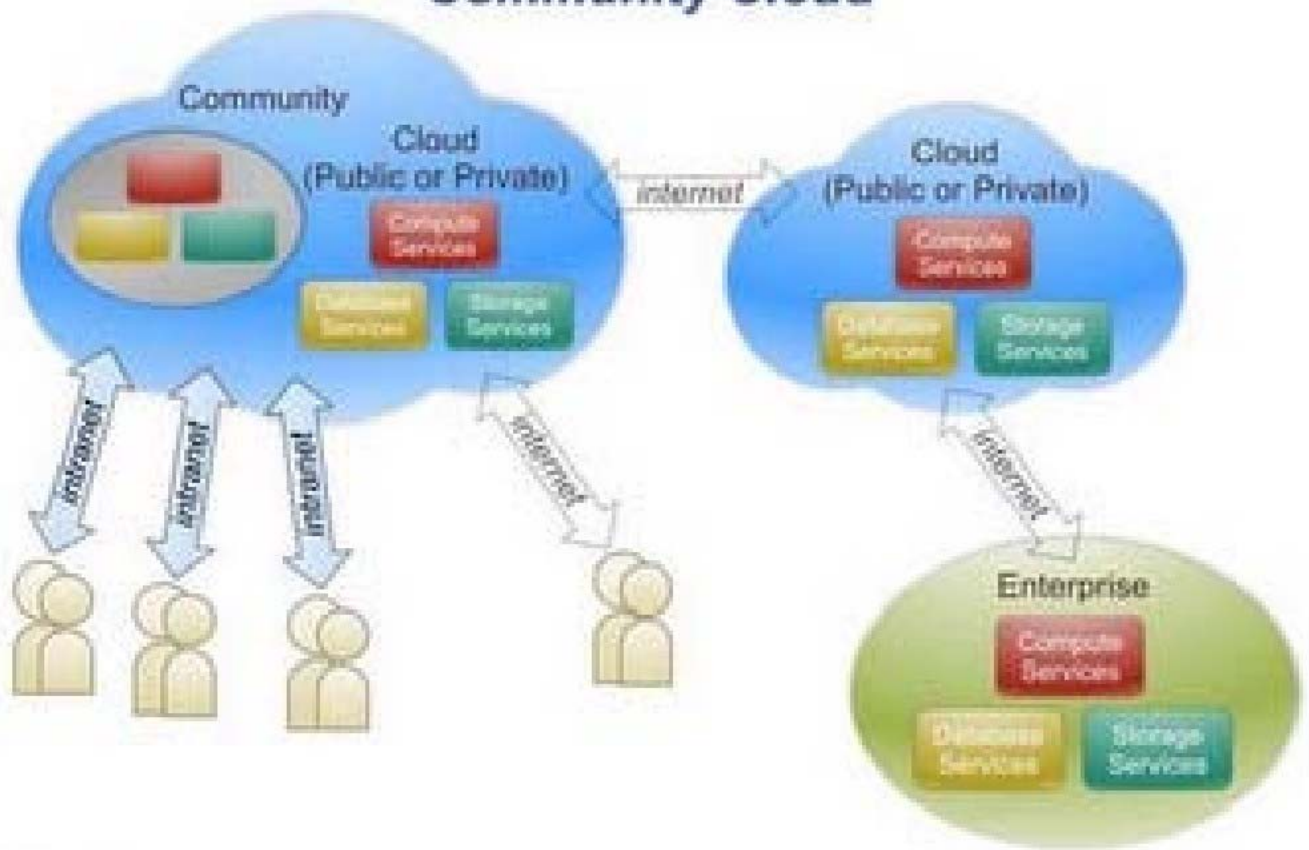


Community Cloud

The cloud infrastructure is provisioned for exclusive use by a specific community of consumers from organizations that have shared concerns (e.g., mission, security requirements, policy, and compliance considerations). It may be owned, managed, and operated by one or more of the organizations in the community, a third party, or some combination of them, and it may exist on or off premises.

Community Cloud

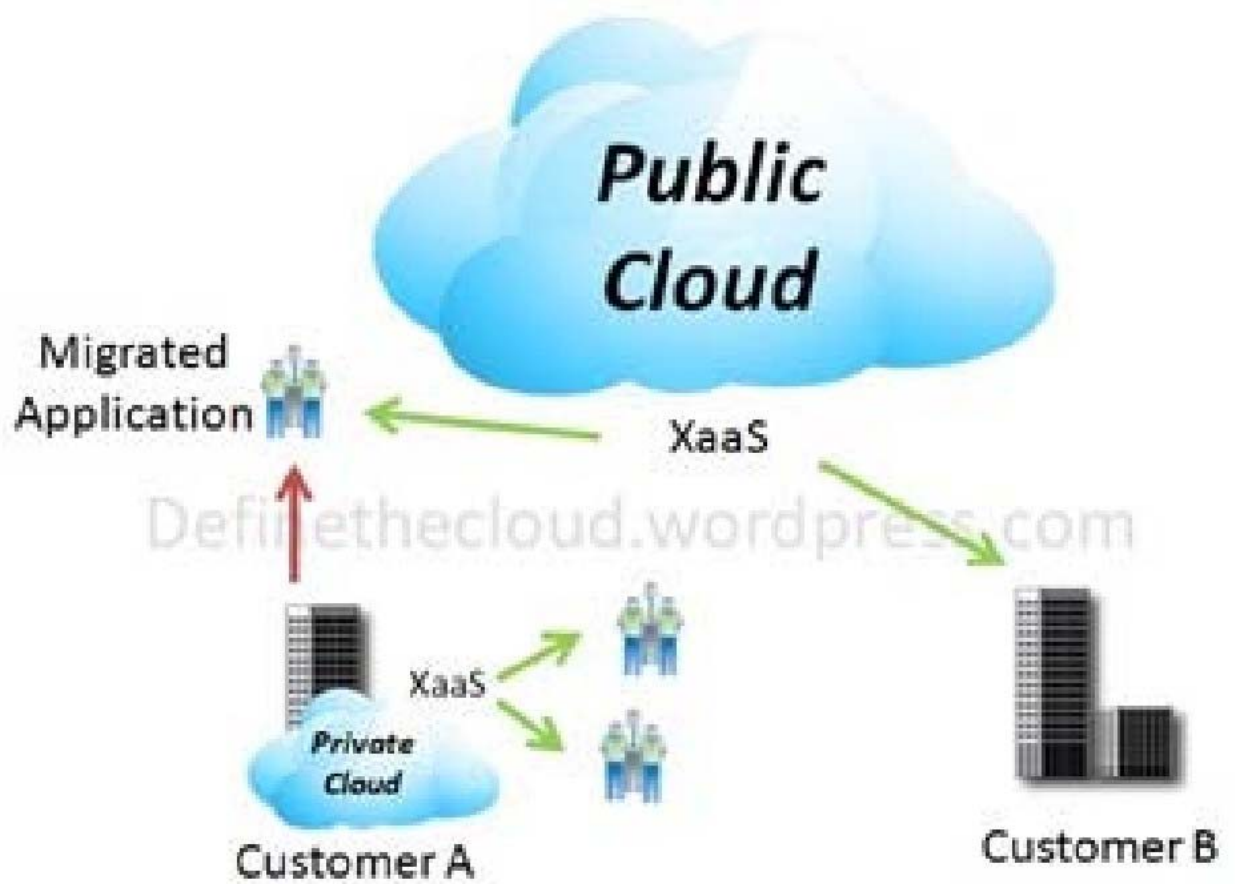
Community Cloud



Public Cloud

The cloud infrastructure is provisioned for open use by the general public. It may be owned, managed, and operated by a business, academic, or government organization, or some combination of them. It exists on the premises of the cloud provider.

Public Cloud



Hybrid cloud

The cloud infrastructure is a composition of two or more distinct cloud infrastructures (private, community, or public) that remain unique entities, but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds) hybrid cloud



The following answers are incorrect:

Private cloud - The cloud infrastructure is provisioned for exclusive use by a single organization comprising multiple consumers (e.g., business units). It may be owned, managed, and operated by the organization, a third party, or some combination of them, and it may exist on or off premises.

Community cloud - The cloud infrastructure is provisioned for exclusive use by a specific community of consumers from organizations that have shared concerns (e.g., mission, security requirements, policy, and compliance considerations). It may be owned, managed, and operated by one or more of the organizations in the community, a third party, or some combination of them, and it may exist on or off premises.

Public cloud - The cloud infrastructure is provisioned for open use by the general public. It may be owned, managed, and operated by a business, academic, or government organization, or some combination of them.

It exists on the premises of the cloud provider.

CISA review manual 2014 page number 102

Official ISC2 guide to CISSP 3rd edition Page number 689 and 690

QUESTION 557

Which of the following step of PDCA establishes the objectives and processes necessary to deliver results in accordance with the expected output?

- A. Plan
- B. Do
- C. Check
- D. Act

Correct Answer: A

Explanation

Explanation/Reference:

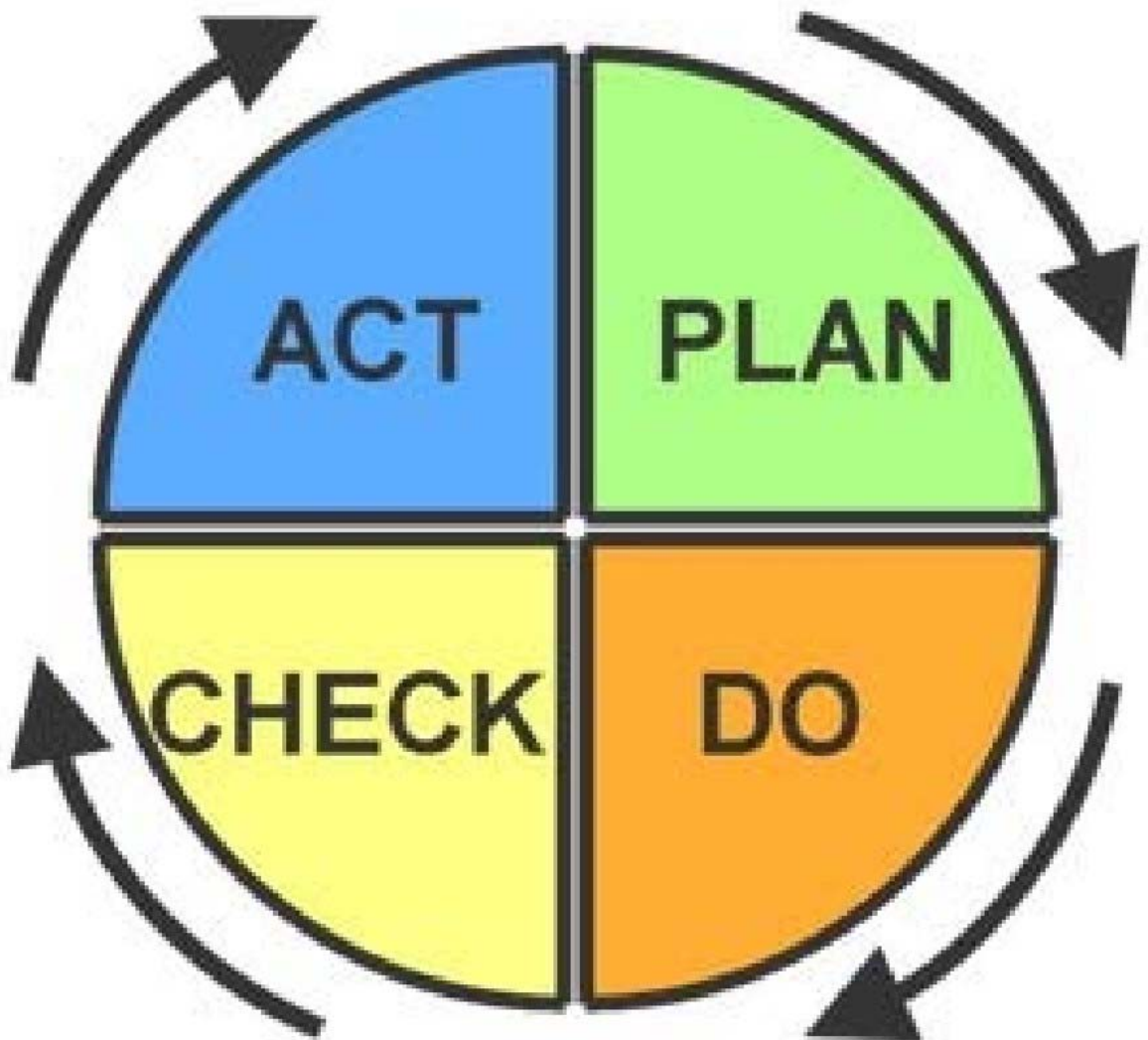
Section: Governance and Management of IT

Plan - Establish the objectives and processes necessary to deliver results in accordance with the expected output (the target or goals). By establishing output expectations, the completeness and accuracy of the spec is also a part of the targeted improvement. When possible start on a small scale to test possible effects.

For your exam you should know the information below:

PDCA (plandocheckact or plandocheckadjust) is an iterative four-step management method used in business for the control and continuous improvement of processes and products. It is also known as the Deming circle/cycle/wheel, Stewart cycle, control circle/cycle, or plandostudyact (PDSA). Another version of this PDCA cycle is OPDCA. The added "O" stands for observation or as some versions say "Grasp the current condition."

The steps in each successive PDCA cycle are:



PLAN

Establish the objectives and processes necessary to deliver results in accordance with the expected output (the target or goals). By establishing output expectations, the completeness and accuracy of the spec is also a part of the targeted improvement. When possible start on a small scale to test possible effects.

DO

Implement the plan, execute the process, make the product. Collect data for charting and analysis in the following "CHECK" and "ACT" steps.

CHECK

Study the actual results (measured and collected in "DO" above) and compare against the expected results (targets or goals from the "PLAN") to ascertain any differences. Look for deviation in implementation from the plan and also look for the appropriateness and completeness of the plan to enable the execution, i.e., "Do". Charting data can make this much easier to see trends over several PDCA cycles and in order to convert the collected data into information. Information is what you need for the next step "ACT".

ACT

Request corrective actions on significant differences between actual and planned results. Analyze the differences to determine their root causes. Determine where to apply changes that will include improvement of the process or product. When a pass through these four steps does not result in the need to improve, the scope to which PDCA is applied may be refined to plan and improve with more detail in the next iteration of the cycle, or attention needs to be placed in a different stage of the process.

The following answers are incorrect:

DO - Implement the plan, execute the process, make the product. Collect data for charting and analysis in the following "CHECK" and "ACT" steps.

CHECK - Study the actual results (measured and collected in "DO" above) and compare against the expected results (targets or goals from the "PLAN") to ascertain any differences ACT -Request corrective actions on significant differences between actual and planned results. Analyze the differences to determine their root causes. Determine where to apply changes that will include improvement of the process or product

CISA review manual 2014 page number 107

QUESTION 558

Which of the following step of PDCA implement the plan, execute the process and make product?

- A. Plan
- B. Do
- C. Check
- D. Act

Correct Answer: B
Explanation

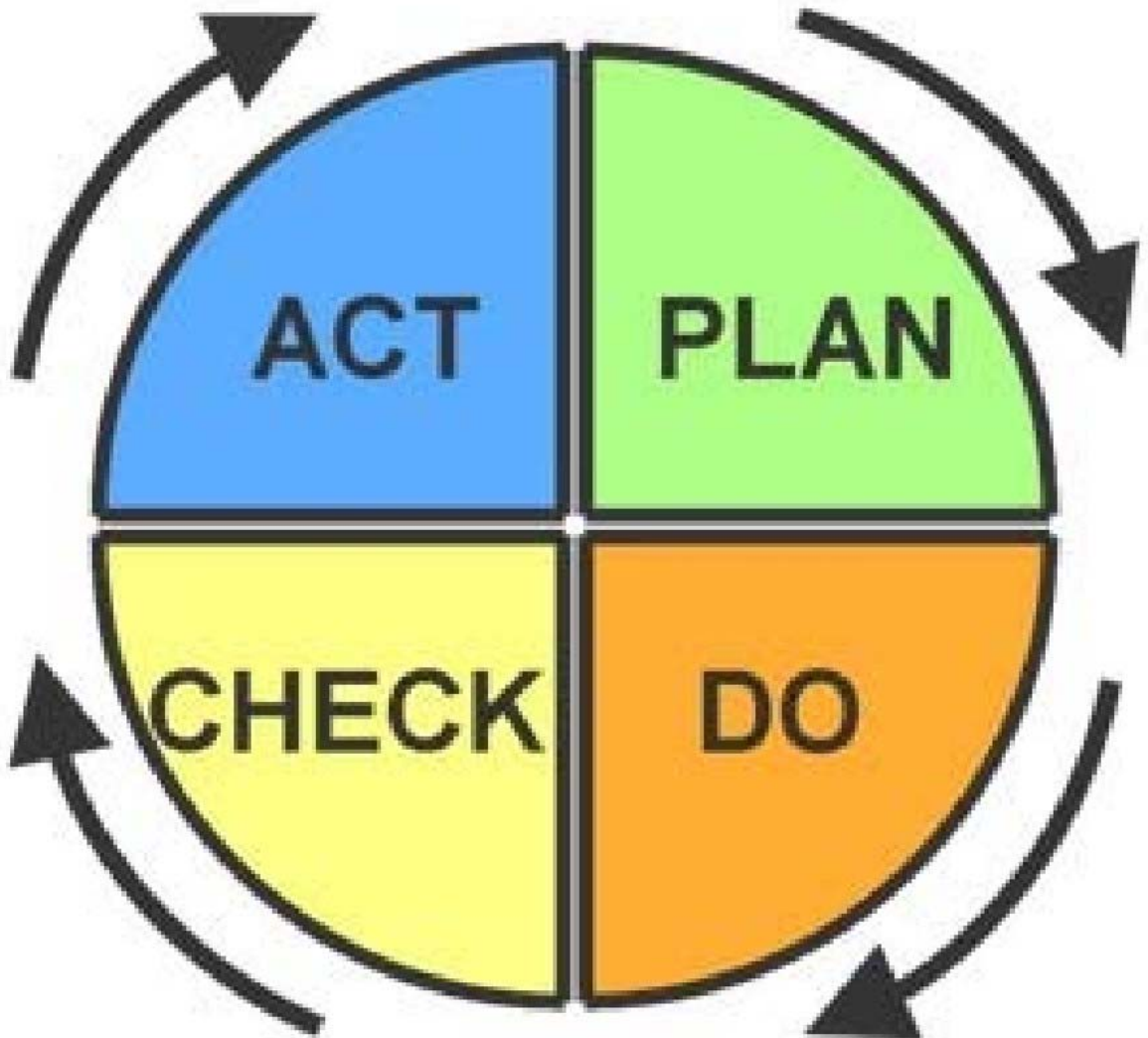
Explanation/Reference:

Section: Governance and Management of IT

Do - Implement the plan, execute the process, make the product. Collect data for charting and analysis in the following "CHECK" and "ACT" steps.

For your exam you should know the information below:

PDCA (plandocheckact or plandocheckadjust) is an iterative four-step management method used in business for the control and continuous improvement of processes and products. It is also known as the Deming circle/cycle/wheel, Stewart cycle, control circle/cycle, or plandostudyact (PDSA). Another version of this PDCA cycle is OPDCA. The added "O" stands for observation or as some versions say "Grasp the current condition." The steps in each successive PDCA cycle are:



PLAN

Establish the objectives and processes necessary to deliver results in accordance with the expected output (the target or goals). By establishing output expectations, the completeness and accuracy of the spec is also a part of the targeted improvement. When possible start on a small scale to test possible effects.

DO

Implement the plan, execute the process, make the product. Collect data for charting and analysis in the following "CHECK" and "ACT" steps.

CHECK

Study the actual results (measured and collected in "DO" above) and compare against the expected results (targets or goals from the "PLAN") to ascertain any differences. Look for deviation in implementation from the plan and also look for the appropriateness and completeness of the plan to enable the execution, i.e., "Do". Charting data can make this much easier to see trends over several PDCA cycles and in order to convert the collected data into information. Information is what you need for the next step "ACT".

ACT

Request corrective actions on significant differences between actual and planned results. Analyze the differences to determine their root causes. Determine where to apply changes that will include improvement of

the process or product. When a pass through these four steps does not result in the need to improve, the scope to which PDCA is applied may be refined to plan and improve with more detail in the next iteration of the cycle, or attention needs to be placed in a different stage of the process.

The following answers are incorrect:

PLAN - Establish the objectives and processes necessary to deliver results in accordance with the expected output (the target or goals).
CHECK - Study the actual results (measured and collected in "DO" above) and compare against the expected results (targets or goals from the "PLAN") to ascertain any differences
ACT - Request corrective actions on significant differences between actual and planned results. Analyze the differences to determine their root causes. Determine where to apply changes that will include improvement of the process or product
CISA review manual 2014 page number 107

QUESTION 559

Which of the following step of PDCA study the actual result and compares it against the expected result?

- A. Plan
- B. Do
- C. Check
- D. Act

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

Check - Study the actual results (measured and collected in "DO" above) and compare against the expected results (targets or goals from the "PLAN") to ascertain any differences. Look for deviation in implementation from the plan and also look for the appropriateness and completeness of the plan to enable the execution, i.e., "Do". Charting data can make this much easier to see trends over several PDCA cycles and in order to convert the collected data into information. Information is what you need for the next step "ACT".

For your exam you should know the information below:

PDCA (plandocheckact or plandocheckadjust) is an iterative four-step management method used in business for the control and continuous improvement of processes and products. It is also known as the Deming circle/cycle/wheel, Stewart cycle, control circle/cycle, or plandostudyact (PDSA). Another version of this PDCA cycle is OPDCA. The added "O" stands for observation or as some versions say "Grasp the current condition."

The steps in each successive PDCA cycle are:



Establish the objectives and processes necessary to deliver results in accordance with the expected output (the target or goals). By establishing output expectations, the completeness and accuracy of the spec is also a part of the targeted improvement. When possible start on a small scale to test possible effects.

DO

Implement the plan, execute the process, make the product. Collect data for charting and analysis in the following "CHECK" and "ACT" steps.

CHECK

Study the actual results (measured and collected in "DO" above) and compare against the expected results (targets or goals from the "PLAN") to ascertain any differences. Look for deviation in implementation from the plan and also look for the appropriateness and completeness of the plan to enable the execution, i.e., "Do". Charting data can make this much easier to see trends over several PDCA cycles and in order to convert the collected data into information. Information is what you need for the next step "ACT".

ACT

Request corrective actions on significant differences between actual and planned results. Analyze the differences to determine their root causes. Determine where to apply changes that will include improvement of the process or product. When a pass through these four steps does not result in the need to improve, the scope to which PDCA is applied may be refined to plan and improve with more detail in the next iteration of the cycle, or attention needs to be placed in a different stage of the process.

The following answers are incorrect:

PLAN - Establish the objectives and processes necessary to deliver results in accordance with the expected output (the target or goals).

DO - Implement the plan, execute the process, make the product. Collect data for charting and analysis in the following "CHECK" and "ACT" steps.

ACT -Request corrective actions on significant differences between actual and planned results. Analyze the differences to determine their root causes. Determine where to apply changes that will include improvement of the process or product

CISA review manual 2014 page number 107

QUESTION 560

Which of the following step of PDCA request a corrective actions on significant differences between the actual versus the planned result?

- A. Plan
- B. Do
- C. Check
- D. Act

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

Act - Request corrective actions on significant differences between actual and planned results. Analyze the

differences to determine their root causes. Determine where to apply changes that will include improvement of the process or product. When a pass through these four steps does not result in the need to improve, the scope to which PDCA is applied may be refined to plan and improve with more detail in the next iteration of the cycle, or attention needs to be placed in a different stage of the process.

For your exam you should know the information below:

PDCA (plandocheckact or plandocheckadjust) is an iterative four-step management method used in business for the control and continuous improvement of processes and products. It is also known as the Deming circle/cycle/wheel, Stewart cycle, control circle/cycle, or plandostudyact (PDSA). Another version of this PDCA cycle is OPDCA. The added "O" stands for observation or as some versions say "Grasp the current condition."

The steps in each successive PDCA cycle are:



PLAN

Establish the objectives and processes necessary to deliver results in accordance with the expected output (the target or goals). By establishing output expectations, the completeness and accuracy of the spec is also a part of the targeted improvement. When possible start on a small scale to test possible effects.

DO

Implement the plan, execute the process, make the product. Collect data for charting and analysis in the following "CHECK" and "ACT" steps.

CHECK

Study the actual results (measured and collected in "DO" above) and compare against the expected results (targets or goals from the "PLAN") to ascertain any differences. Look for deviation in implementation from the plan and also look for the appropriateness and completeness of the plan to enable the execution, i.e., "Do". Charting data can make this much easier to see trends over several PDCA cycles and in order to convert the collected data into information. Information is what you need for the next step "ACT".

ACT

Request corrective actions on significant differences between actual and planned results. Analyze the differences to determine their root causes. Determine where to apply changes that will include improvement of

the process or product. When a pass through these four steps does not result in the need to improve, the scope to which PDCA is applied may be refined to plan and improve with more detail in the next iteration of the cycle, or attention needs to be placed in a different stage of the process.

The following answers are incorrect:

PLAN - Establish the objectives and processes necessary to deliver results in accordance with the expected output (the target or goals).

DO - Implement the plan, execute the process, make the product. Collect data for charting and analysis in the following "CHECK" and "ACT" steps.

CHECK - Study the actual results (measured and collected in "DO" above) and compare against the expected results (targets or goals from the "PLAN") to ascertain any differences CISA review manual 2014 page number 107

QUESTION 561

Which of the following answer specifies the correct sequence of levels within the Capability Maturity Model (CMM)?

- A. Initial, Managed, Defined, Quantitatively managed, optimized
- B. Initial, Managed, Defined, optimized, Quantitatively managed
- C. Initial, Defined, Managed, Quantitatively managed, optimized

D. Initial, Managed, Quantitatively managed, Defined, optimized

Correct Answer: A

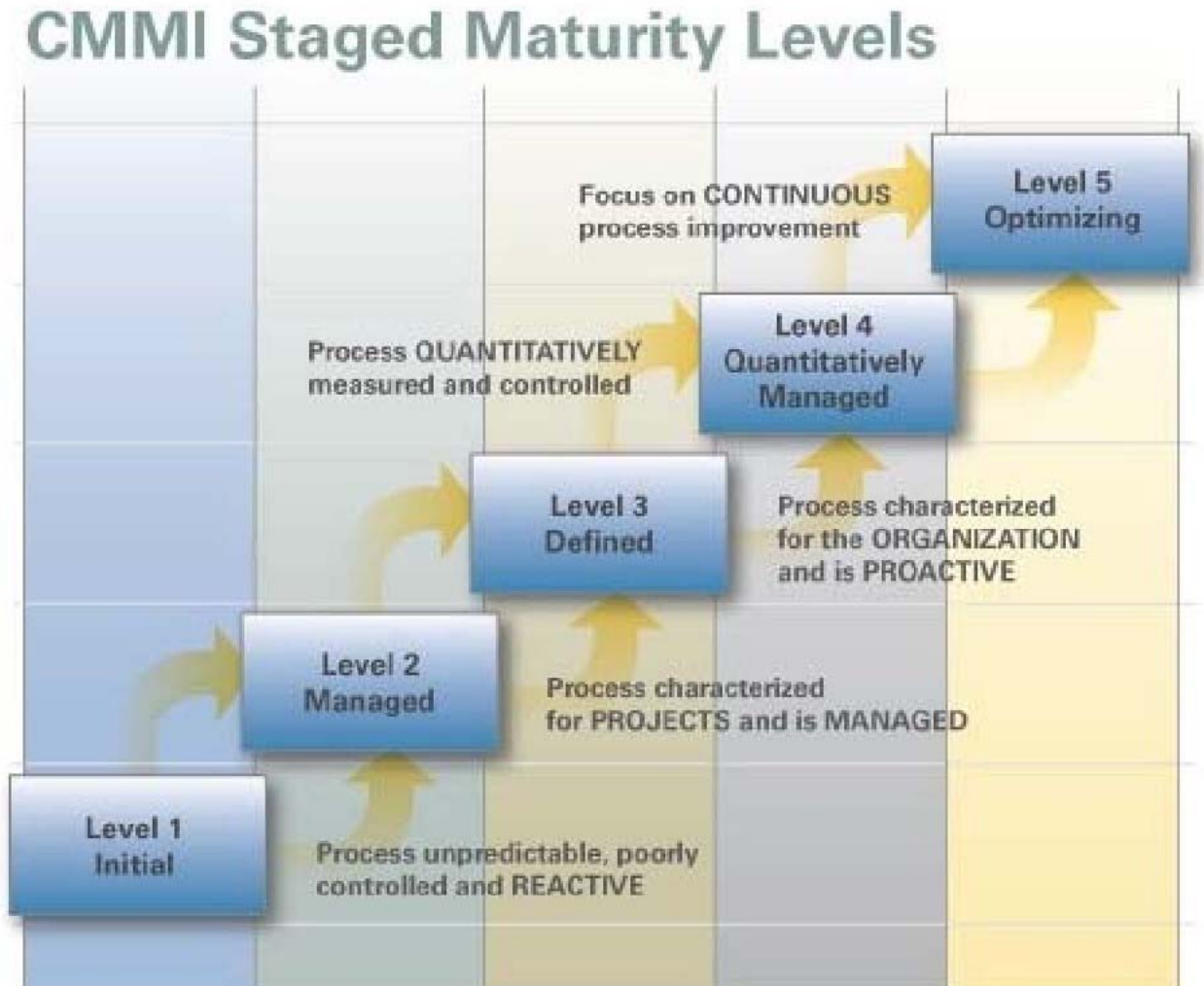
Explanation

Explanation/Reference:

Section: Governance and Management of IT

Maturity model

A maturity model can be viewed as a set of structured levels that describe how well the behaviors, practices and processes of an organization can reliably and sustainably produce required outcomes.



A maturity model can be used as a benchmark for comparison and as an aid to understanding - for example, for comparative assessment of different organizations where there is something in common that can be used as a basis for comparison. In the case of the CMM, for example, the basis for comparison would be the organizations' software development processes.

Structure

The model involves five aspects:

Maturity Levels: a 5-level process maturity continuum - where the uppermost (5th) level is a notional ideal state where processes would be systematically managed by a combination of process optimization and continuous process improvement.

Key Process Areas: a Key Process Area identifies a cluster of related activities that, when performed together, achieve a set of goals considered important.

Goals: the goals of a key process area summarize the states that must exist for that key process area to have been implemented in an effective and lasting way. The extent to which the goals have been accomplished is an indicator of how much capability the organization has established at that maturity level. The goals signify the scope, boundaries, and intent of each key process area.

Common Features: common features include practices that implement and institutionalize a key process area. There are five types of common features: commitment to perform, ability to perform, activities performed, measurement and analysis, and verifying implementation.

Key Practices: The key practices describe the elements of infrastructure and practice that contribute most effectively to the implementation and institutionalization of the area.

Levels

There are five levels defined along the continuum of the model and, according to the SEI: "Predictability, effectiveness, and control of an organization's software processes are believed to improve as the organization moves up these five levels. While not rigorous, the empirical evidence to date supports this belief".

Initial (chaotic, ad hoc, individual heroics) - the starting point for use of a new or undocumented repeat process.

Repeatable - the process is at least documented sufficiently such that repeating the same steps may be attempted.

Defined - the process is defined/confirmed as a standard business process, and decomposed to levels 0, 1 and 2 (the last being Work Instructions).

Managed - the process is quantitatively managed in accordance with agreed-upon metrics. Optimizing - process management includes deliberate process optimization/improvement.

Within each of these maturity levels are Key Process Areas which characteristic that level, and for each such area there are five factors: goals, commitment, ability, measurement, and verification. These are not necessarily unique to CMM, representing -- as they do -- the stages that organizations must go through on the way to becoming mature.

The model provides a theoretical continuum along which process maturity can be developed incrementally from one level to the next. Skipping levels is not allowed/feasible.

Level 1 - Initial (Chaotic)

It is characteristic of processes at this level that they are (typically) undocumented and in a state of dynamic change, tending to be driven in an ad hoc, uncontrolled and reactive manner by users or events. This provides a chaotic or unstable environment for the processes.

Level 2 - Repeatable

It is characteristic of processes at this level that some processes are repeatable, possibly with consistent results. Process discipline is unlikely to be rigorous, but where it exists it may help to ensure that existing processes are maintained during times of stress.

Level 3 - Defined

It is characteristic of processes at this level that there are sets of defined and documented standard processes established and subject to some degree of improvement over time. These standard processes are in place (i.e., they are the AS-IS processes) and used to establish consistency of process performance across the organization.

Level 4 - Managed

It is characteristic of processes at this level that, using process metrics, management can effectively control the AS-IS process (e.g., for software development). In particular, management can identify ways to adjust and adapt the process to particular projects without measurable losses of quality or deviations from specifications.

Process Capability is established from this level.

Level 5 - Optimizing

It is characteristic of processes at this level that the focus is on continually improving process performance through both incremental and innovative technological changes/improvements.

At maturity level 5, processes are concerned with addressing statistical common causes of process variation and changing the process (for example, to shift the mean of the process performance) to improve process performance. This would be done at the same time as maintaining the likelihood of achieving the established quantitative process-improvement objectives.

The following answers are incorrect:

The other option specified in the option does not provide correct sequence.

CISA review manual 2014 Page number 188

CISSP Official study guide page number 693

QUESTION 562

Which of the following dynamic interaction of a Business Model for Information Security (BMIS) is a pattern of behaviors, effects, assumptions, attitude and ways of doing things?

- A. Governing
- B. Culture
- C. Enabling and support
- D. Emergence

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

Culture is a pattern of behaviors, beliefs, assumptions, attitudes and ways of doing things. It is emergent and learned, and it creates a sense of comfort. Culture evolves as a type of shared history as a group goes through a set of common experiences. Those similar experiences cause certain responses, which become a set of expected and shared behaviors. These behaviors become unwritten rules, which become norms that are shared by all people who have that common history. It is important to understand the culture of the enterprise because it profoundly influences what information is considered, how it is interpreted and what will be done with it. Culture may exist on many levels, such as national (legislation/regulation, political and traditional), organizational (policies, hierarchical style and expectations) and social (family, etiquette). It is created from both external and internal factors, and is influenced by and influences organizational patterns.

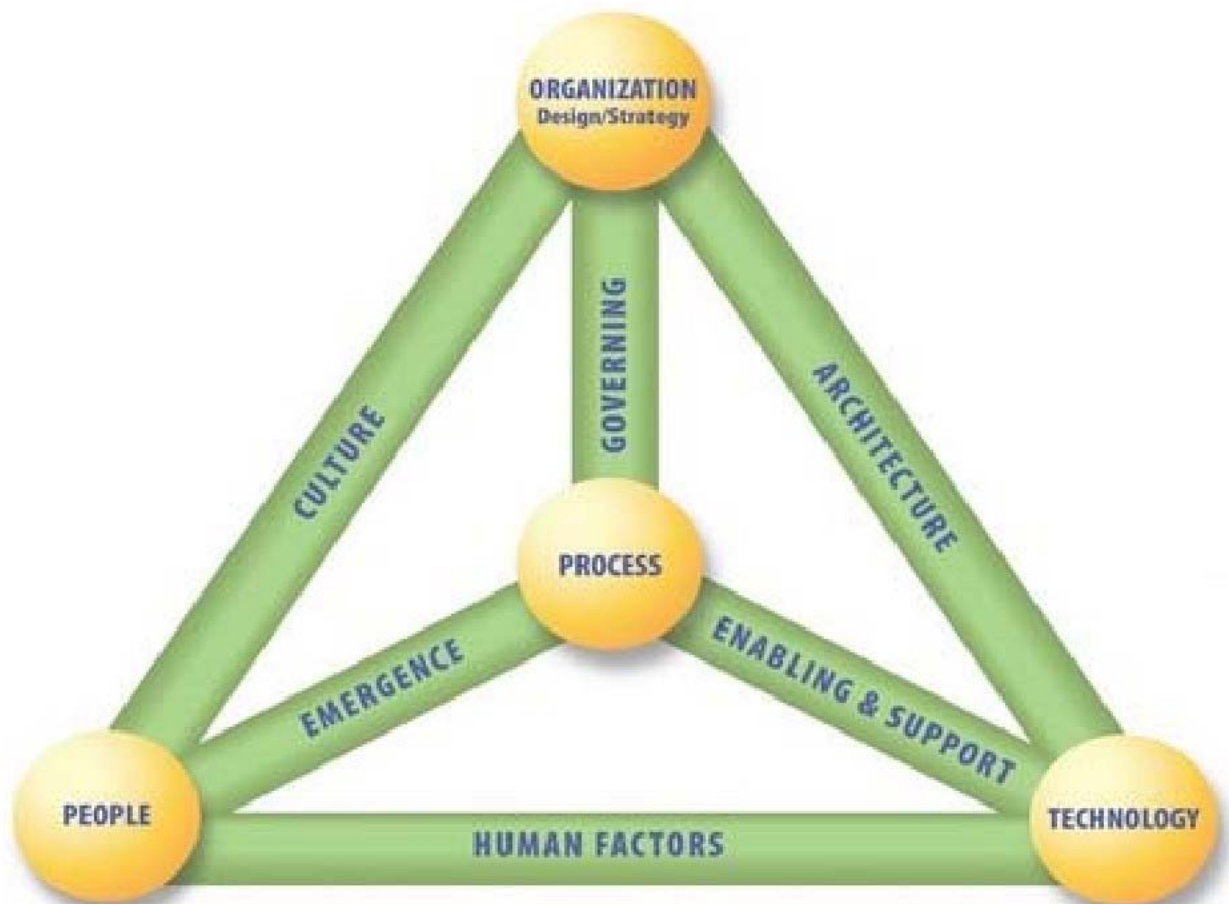
For your exam you should know the information below.

Business Model for Information Security

The Business Model for Information Security (BMIS) originated at the Institute for Critical Information Infrastructure Protection at the Marshall School of Business at the University of Southern California in the USA. ISACA has undertaken the development of the Systemic Security Management Model. The BMIS takes a business-oriented approach to managing information security, building on the foundational concepts developed by the Institute. The model utilizes systems thinking to clarify complex relationships within the enterprise, and thus to more effectively manage security. The elements and dynamic interconnections that form the basis of the model establish the boundaries of an information security program and model how the program functions and reacts to internal and external change. The BMIS provides the context for frameworks such as Cubit.

The essence of systems theory is that a system needs to be viewed holistically not merely as a sum of its parts to be accurately understood. A holistic approach examines the system as a complete functioning unit. Another tenet of systems theory is that one part of the system enables understanding of other parts of the system. "Systems thinking" is a widely recognized term that refers to the examination of how systems interact, how complex systems work and why "the whole is more than the sum of its parts." Systems theory is most accurately described as a complex network of events, relationships, reactions, consequences, technologies, processes and people that interact in often unseen and unexpected ways. Studying the behaviors and results of the interactions can assist the manager to better understand the organizational system and the way it functions. While management of any discipline within the enterprise can be enhanced by approaching it from a systems thinking perspective, its implementation will certainly help with managing risk.

The success that the systems approach has achieved in other fields bodes well for the benefits it can bring to security. The often dramatic failures of enterprises to adequately address security issues in recent years are due, to a significant extent, to their inability to define security and present it in a way that is comprehensible and relevant to all stakeholders. Utilizing a systems approach to information security management will help information security managers address complex and dynamic environments, and will generate a beneficial effect on collaboration within the enterprise, adaptation to operational change, navigation of strategic uncertainty and tolerance of the impact of external factors. The model is represented below.



As illustrated in above, the model is best viewed as a flexible, three-dimensional, pyramid-shaped structure made up of four elements linked together by six dynamic interconnections. All aspects of the model interact with each other. If any one part of the model is changed, not addressed or managed inappropriately, the equilibrium of the model is potentially at risk. The dynamic interconnections act as tensions, exerting a push/pull force in reaction to changes in the enterprise, allowing the model to adapt as needed.

The four elements of the model are:

1. **Organization Design and Strategy** An organization is a network of people, assets and processes interacting with each other in defined roles and working toward a common goal. An enterprise's strategy specifies its business goals and the objectives to be achieved as well as the values and missions to be pursued. It is the enterprise's formula for success and sets its basic direction. The strategy should adapt to external and internal factors. Resources are the primary material to design the strategy and can be of different types (people, equipment, know-how). Design defines how the organization implements its strategy. Processes, culture and architecture are important in determining the design.

2. **People** The human resources and the security issues that surround them. It defines who implements (through design) each part of the strategy. It represents a human collective and must take into account values, behaviors and biases. Internally, it is critical for the information security manager to work with the human resources and legal departments to address issues such as:

Recruitment strategies (access, background checks, interviews, roles and responsibilities) Employment issues (location of office, access to tools and data, training and awareness, movement within the enterprise)

Termination (reasons for leaving, timing of exit, roles and responsibilities, access to systems, access to other employees). Externally, customers, suppliers, media, stakeholders and others can have a strong influence on the enterprise and need to be considered within the security posture.

3. **Process** Includes formal and informal mechanisms (large and small, simple and complex) to get things done and provides a vital link to all of the dynamic interconnections. Processes identify, measure, manage and control risk, availability, integrity and confidentiality, and they also ensure accountability. They derive from the strategy and implement the operational part of the organization element.

To be advantageous to the enterprise, processes must:

Meet business requirements and align with policy

Consider emergence and be adaptable to changing requirements

Be well documented and communicated to appropriate human resources Be reviewed periodically, once they are in place, to ensure efficiency and effectiveness

4. **Technology** Composed of all of the tools, applications and infrastructure that make processes more efficient. As an evolving element that experiences frequent changes, it has its own dynamic risk. Given the typical enterprise's dependence on technology, technology constitutes a core part of the enterprise's infrastructure and a critical component in accomplishing its mission. Technology is often seen by the enterprise's management team as a way to resolve security threats and risk. While technical controls are helpful in mitigating some types of risk, technology should not be viewed as an information security solution.

Technology is greatly impacted by users and by organizational culture. Some individuals still mistrust technology; some have not learned to use it; and others feel it slows them down. Regardless of the reason, information security managers must be aware that many people will try to sidestep technical controls.

Dynamic Interconnections

The dynamic interconnections are what link the elements together and exert a multidirectional force that pushes and pulls as things change. Actions and behaviors that occur in the dynamic interconnections can force the model out of balance or bring it back to equilibrium.

The six dynamic interconnections are:

1. **Governing** Governing is the steering of the enterprise and demands strategic leadership. Governing sets limits within which an enterprise operates and is implemented within processes to monitor performance, describe activities and achieve compliance while also providing adaptability to emergent conditions.

Governing incorporates ensuring that objectives are determined and defined, ascertaining that risks are managed appropriately, and verifying that the enterprise's resources are used responsibly.

2. Culture Culture is a pattern of behaviors, beliefs, assumptions, attitudes and ways of doing things. It is emergent and learned, and it creates a sense of comfort. Culture evolves as a type of shared history as a group goes through a set of common experiences. Those similar experiences cause certain responses, which become a set of expected and shared behaviors. These behaviors become unwritten rules, which become norms that are shared by all people who have that common history. It is important to understand the culture of the enterprise because it profoundly influences what information is considered, how it is interpreted and what will be done with it. Culture may exist on many levels, such as national (legislation/regulation, political and traditional), organizational (policies, hierarchical style and expectations) and social (family, etiquette). It is created from both external and internal factors, and is influenced by and influences organizational patterns.

3. Enabling and support The enabling and support dynamic interconnection connects the technology element to the process element. One way to help ensure that people comply with technical security measures, policies and procedures is to make processes usable and easy. Transparency can help generate acceptance for security controls by assuring users that security will not inhibit their ability to work effectively. Many of the actions that affect both technology and processes occur in the enabling and support dynamic interconnection. Policies, standards and guidelines must be designed to support the needs of the business by reducing or eliminating conflicts of interest, remaining flexible to support changing business objectives, and being acceptable and easy for people to follow.

4. Emergence Emergence which connotes surfacing, developing, growing and evolving refers to patterns that arise in the life of the enterprise that appear to have no obvious cause and whose outcomes seem impossible to predict and control. The emergence dynamic interconnection (between people and processes) is a place to introduce possible solutions such as feedback loops; alignment with process improvement; and consideration of emergent issues in system design life cycle, change control, and risk management.

5. Human factors The human factors dynamic interconnection represents the interaction and gap between technology and people and, as such, is critical to an information security program. If people do not understand how to use the technology, do not embrace the technology or will not follow pertinent policies, serious security problems can evolve. Internal threats such as data leakage, data theft and misuse of data can occur within this dynamic interconnection. Human factors may arise because of age, experience level and/or cultural experiences. Because human factors are critical components in maintaining balance within the model, it is important to train all of the enterprise's human resources on pertinent skills.

6. Architecture A security architecture is a comprehensive and formal encapsulation of the people, processes, policies and technology that comprise an enterprise's security practices. A robust business information architecture is essential to understanding the need for security and designing the security architecture. It is within the architecture dynamic interconnection that the enterprise can ensure defense in depth. The design describes how the security controls are positioned and how they relate to the overall IT architecture. An enterprise security architecture facilitates security capabilities across lines of businesses in a consistent and a cost-effective manner and enables enterprises to be proactive with their security investment decisions.

The following answers are incorrect:

Governing - Governing is the steering of the enterprise and demands strategic leadership. Governing sets limits within which an enterprise operates and is implemented within processes to monitor performance, describe activities and achieve compliance while also providing adaptability to emergent conditions. Governing incorporates ensuring that objectives are determined and defined, ascertaining that risks are managed appropriately, and verifying that the enterprise's resources are used responsibly.

Enabling and support - The enabling and support dynamic interconnection connects the technology element to the process element. One way to help ensure that people comply with technical security measures, policies

and procedures is to make processes usable and easy. Transparency can help generate acceptance for security controls by assuring users that security will not inhibit their ability to work effectively. Many of the actions that affect both technology and processes occur in the enabling and support dynamic interconnection. Policies, standards and guidelines must be designed to support the needs of the business by reducing or eliminating conflicts of interest, remaining flexible to support changing business objectives, and being acceptable and easy for people to follow.

Emergence Emergence which connotes surfacing, developing, growing and evolving refers to patterns that arise in the life of the enterprise that appear to have no obvious cause and whose outcomes seem impossible to predict and control. The emergence dynamic interconnection (between people and processes) is a place to introduce possible solutions such as feedback loops; alignment with process improvement; and consideration of emergent issues in system design life cycle, change control, and risk management.

CISA review manual 2014 page number 37 and 38

<http://www.isaca.org/Knowledge-Center/BMIS/Documents/IntrotoBMIS.pdf>

QUESTION 563

Which of the following dynamic interaction of a Business Model for Information Security (BMIS) is a place to introduce possible solutions such as feedback loops; alignment with process improvement; and consideration of emergent issues in system design life cycle, change control, and risk management?

- A. Governing
- B. Culture
- C. Enabling and support
- D. Emergence

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

Emergence which connotes surfacing, developing, growing and evolving refers to patterns that arise in the life of the enterprise that appear to have no obvious cause and whose outcomes seem impossible to predict and control. The emergence dynamic interconnection (between people and processes) is a place to introduce possible solutions such as feedback loops; alignment with process improvement; and consideration of emergent issues in system design life cycle, change control, and risk management.

For your exam you should know the information below.

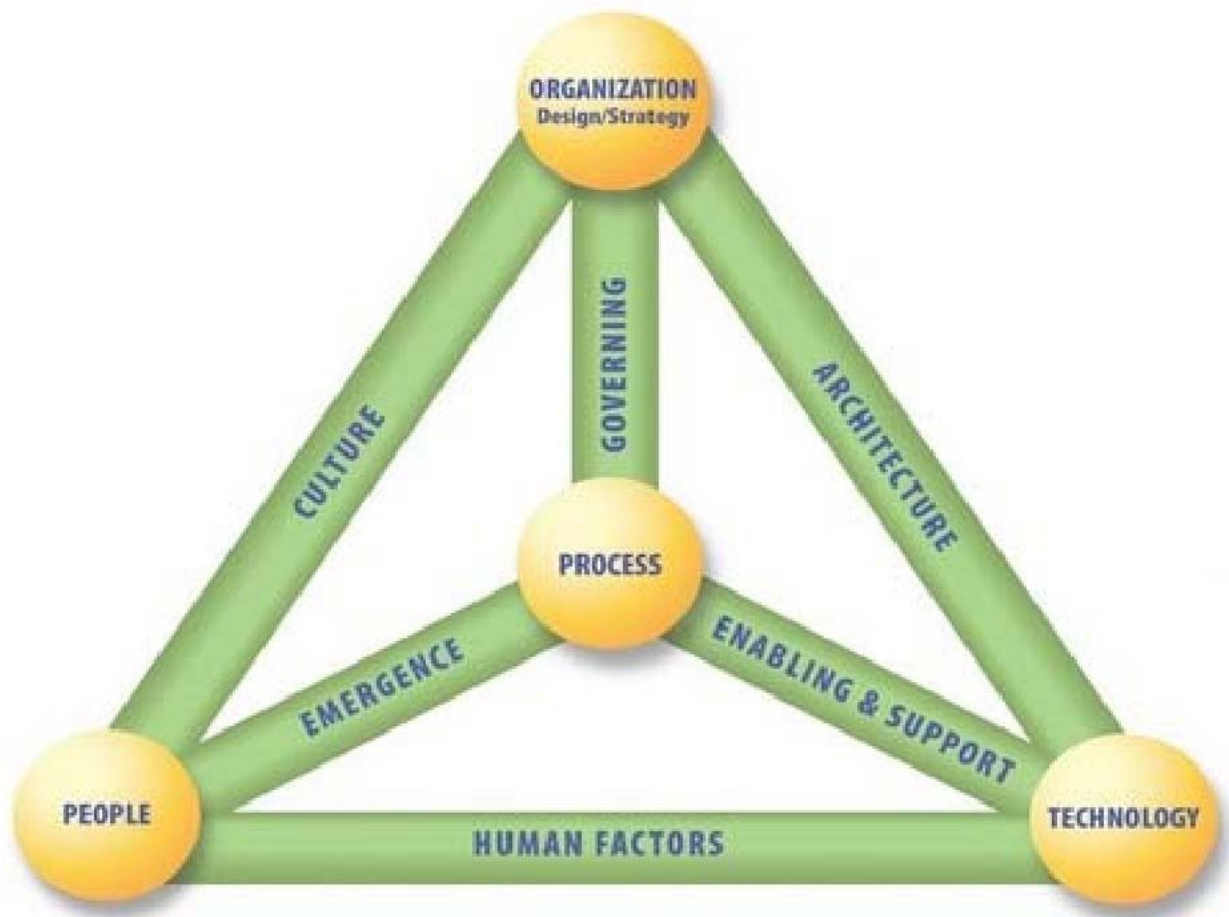
Business Model for Information Security

The Business Model for Information Security (BMIS) originated at the Institute for Critical Information Infrastructure Protection at the Marshall School of Business at the University of Southern California in the USA. ISACA has undertaken the development of the Systemic Security Management Model. The BMIS takes a business-oriented approach to managing information security, building on the foundational concepts developed by the Institute. The model utilizes systems thinking to clarify complex relationships within the enterprise, and thus to more effectively manage security. The elements and dynamic interconnections that form the basis of the model establish the boundaries of an information security program and model how the program functions and reacts to internal and external change. The BMIS provides the context for frameworks such as Cubit.

The essence of systems theory is that a system needs to be viewed holistically not merely as a sum of its parts to be accurately understood. A holistic approach examines the system as a complete functioning unit. Another tenet of systems theory is that one part of the system enables understanding of other parts of the

system. "Systems thinking" is a widely recognized term that refers to the examination of how systems interact, how complex systems work and why "the whole is more than the sum of its parts." Systems theory is most accurately described as a complex network of events, relationships, reactions, consequences, technologies, processes and people that interact in often unseen and unexpected ways. Studying the behaviors and results of the interactions can assist the manager to better understand the organizational system and the way it functions. While management of any discipline within the enterprise can be enhanced by approaching it from a systems thinking perspective, its implementation will certainly help with managing risk.

The success that the systems approach has achieved in other fields bodes well for the benefits it can bring to security. The often dramatic failures of enterprises to adequately address security issues in recent years are due, to a significant extent, to their inability to define security and present it in a way that is comprehensible and relevant to all stakeholders. Utilizing a systems approach to information security management will help information security managers address complex and dynamic environments, and will generate a beneficial effect on collaboration within the enterprise, adaptation to operational change, navigation of strategic uncertainty and tolerance of the impact of external factors. The model is represented below.



As illustrated in above, the model is best viewed as a flexible, three-dimensional, pyramid-shaped structure made up of four elements linked together by six dynamic interconnections.

All aspects of the model interact with each other. If any one part of the model is changed, not addressed or managed inappropriately, the equilibrium of the model is potentially at risk. The dynamic interconnections act as tensions, exerting a push/pull force in reaction to changes in the enterprise, allowing the model to adapt as needed.

The four elements of the model are:

1. Organization Design and Strategy organization is a network of people, assets and processes interacting with each other in defined roles and working toward a common goal.

An enterprise's strategy specifies its business goals and the objectives to be achieved as well as the values and missions to be pursued. It is the enterprise's formula for success and sets its basic direction. The strategy should adapt to external and internal factors. Resources are the primary material to design the strategy and can be of different types (people, equipment, know-how). Design defines how the organization implements its strategy. Processes, culture and architecture are important in determining the design.

2. People The human resources and the security issues that surround them. It defines who implements (through design) each part of the strategy. It represents a human collective and must take into account values, behaviors and biases. Internally, it is critical for the information security manager to work with the human resources and legal departments to address issues such as:
Recruitment strategies (access, background checks, interviews, roles and responsibilities) Employment issues (location of office, access to tools and data, training and awareness, movement within the enterprise)
Termination (reasons for leaving, timing of exit, roles and responsibilities, access to systems, access to other employees). Externally, customers, suppliers, media, stakeholders and others can have a strong influence on the enterprise and need to be considered within the security posture.

3. Process Includes formal and informal mechanisms (large and small, simple and complex) to get things done and provides a vital link to all of the dynamic interconnections. Processes identify, measure, manage and control risk, availability, integrity and confidentiality, and they also ensure accountability. They derive from the strategy and implement the operational part of the organization element.

To be advantageous to the enterprise, processes must:

Meet business requirements and align with policy

Consider emergence and be adaptable to changing requirements

Be well documented and communicated to appropriate human resources Be reviewed periodically, once they are in place, to ensure efficiency and effectiveness

4. Technology Composed of all of the tools, applications and infrastructure that make processes more efficient. As an evolving element that experiences frequent changes, it has its own dynamic risk. Given the typical enterprise's dependence on technology, technology constitutes a core part of the enterprise's infrastructure and a critical component in accomplishing its mission. Technology is often seen by the enterprise's management team as a way to resolve security threats and risk. While technical controls are helpful in mitigating some types of risk, technology should not be viewed as an information security solution.

Technology is greatly impacted by users and by organizational culture. Some individuals still mistrust technology; some have not learned to use it; and others feel it slows them down. Regardless of the reason, information security managers must be aware that many people will try to sidestep technical controls.

Dynamic Interconnections

The dynamic interconnections are what link the elements together and exert a multidirectional force that pushes and pulls as things change. Actions and behaviors that occur in the dynamic interconnections can force the model out of balance or bring it back to equilibrium.

The six dynamic interconnections are:

1. **Governing** Governing is the steering of the enterprise and demands strategic leadership. Governing sets limits within which an enterprise operates and is implemented within processes to monitor performance, describe activities and achieve compliance while also providing adaptability to emergent conditions. Governing incorporates ensuring that objectives are determined and defined, ascertaining that risks are managed appropriately, and verifying that the enterprise's resources are used responsibly.
2. **Culture** Culture is a pattern of behaviors, beliefs, assumptions, attitudes and ways of doing things. It is emergent and learned, and it creates a sense of comfort. Culture evolves as a type of shared history as a group goes through a set of common experiences. Those similar experiences cause certain responses, which become a set of expected and shared behaviors. These behaviors become unwritten rules, which become norms that are shared by all people who have that common history. It is important to understand the culture of the enterprise because it profoundly influences what information is considered, how it is interpreted and what will be done with it. Culture may exist on many levels, such as national (legislation/regulation, political and traditional), organizational (policies, hierarchical style and expectations) and social (family, etiquette). It is created from both external and internal factors, and is influenced by and influences organizational patterns.
3. **Enabling and support** The enabling and support dynamic interconnection connects the technology element to the process element. One way to help ensure that people comply with technical security measures, policies and procedures is to make processes usable and easy. Transparency can help generate acceptance for security controls by assuring users that security will not inhibit their ability to work effectively. Many of the actions that affect both technology and processes occur in the enabling and support dynamic interconnection. Policies, standards and guidelines must be designed to support the needs of the business by reducing or eliminating conflicts of interest, remaining flexible to support changing business objectives, and being acceptable and easy for people to follow.
4. **Emergence** Emergence which connotes surfacing, developing, growing and evolving refers to patterns that arise in the life of the enterprise that appear to have no obvious cause and whose outcomes seem impossible to predict and control. The emergence dynamic interconnection (between people and processes) is a place to introduce possible solutions such as feedback loops; alignment with process improvement; and consideration of emergent issues in system design life cycle, change control, and risk management.
5. **Human factors** The human factors dynamic interconnection represents the interaction and gap between technology and people and, as such, is critical to an information security program. If people do not understand how to use the technology, do not embrace the technology or will not follow pertinent policies, serious security problems can evolve. Internal threats such as data leakage, data theft and misuse of data can occur within this dynamic interconnection. Human factors may arise because of age, experience level and/or cultural experiences. Because human factors are critical components in maintaining balance within the model, it is important to train all of the enterprise's human resources on pertinent skills.
6. **Architecture** A security architecture is a comprehensive and formal encapsulation of the people, processes, policies and technology that comprise an enterprise's security practices. A robust business information architecture is essential to understanding the need for security and designing the security architecture. It is within the architecture dynamic interconnection that the enterprise can ensure defense in depth. The design describes how the security controls are positioned and how they relate to the overall IT architecture. An enterprise security architecture facilitates security capabilities across lines of businesses in a consistent and a cost-effective manner and enables enterprises to be proactive with their security investment decisions.

The following answers are incorrect:

Governing - Governing is the steering of the enterprise and demands strategic leadership. Governing sets limits within which an enterprise operates and is implemented within processes to monitor performance, describe activities and achieve compliance while also providing adaptability to emergent conditions. Governing incorporates ensuring that objectives are determined and defined, ascertaining that risks are managed appropriately, and verifying that the enterprise's resources are used responsibly.

Enabling and support - The enabling and support dynamic interconnection connects the technology element to the process element. One way to help ensure that people comply with technical security measures, policies and procedures is to make processes usable and easy. Transparency can help generate acceptance for security controls by assuring users that security will not inhibit their ability to work effectively. Many of the actions that affect both technology and processes occur in the enabling and support dynamic interconnection. Policies, standards and guidelines must be designed to support the needs of the business by reducing or eliminating conflicts of interest, remaining flexible to support changing business objectives, and being acceptable and easy for people to follow.

Culture - Culture is a pattern of behaviors, beliefs, assumptions, attitudes and ways of doing things. It is emergent and learned, and it creates a sense of comfort. Culture evolves as a type of shared history as a group goes through a set of common experiences. Those similar experiences cause certain responses, which become a set of expected and shared behaviors. These behaviors become unwritten rules, which become norms that are shared by all people who have that common history. It is important to understand the culture of the enterprise because it profoundly influences what information is considered, how it is interpreted and what will be done with it. Culture may exist on many levels, such as national (legislation/regulation, political and traditional), organizational (policies, hierarchical style and expectations) and social (family, etiquette). It is

created from both external and internal factors, and is influenced by and influences organizational patterns.

CISA review manual 2014 page number 37 and 38

<http://www.isaca.org/Knowledge-Center/BMIS/Documents/IntrotoBMIS.pdf>

QUESTION 564

A maturity model can be used to aid the implementation of IT governance by identifying:

- A. critical success factors (CSF)
- B. performance drivers
- C. improvement opportunities
- D. accountabilities

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 565

The effectiveness of an information security governance framework will BEST be enhanced if:

- A. consultants review the information security governance framework
- B. a culture of legal and regulatory compliance is promoted by management
- C. IS auditors are empowered to evaluate governance activities
- D. risk management is built into operational and strategic activities

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 566

Which of the following is the MOST important requirement for the successful implementation of security governance?

- A. Aligning to an international security framework
- B. Mapping to organizational strategies
- C. Implementing a security balanced scorecard
- D. Performing an enterprise-wide risk assessment

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 567

Which of the following BEST demonstrates effective information security management within an organization?

- A. Employees support decisions made by information security management.
- B. Excessive risk exposure in one department can be absorbed by other departments.
- C. Information security governance is incorporated into organizational governance.
- D. Control ownership is assigned to parties who can accept losses related to control failure.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 568

A multinational organization is introducing a security governance framework. The information security manager's concern is that regional security practices differ. Which of the following should be evaluated FIRST?

- A. Local regulatory requirements
- B. Local IT requirements
- C. Cross-border data mobility
- D. Corporate security objectives

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 569

When facilitating the alignment of corporate governance and information security governance, which of the following is the MOST important role of an organization's security steering committee?

- A. Obtaining support for the integration from business owners
- B. Obtaining approval for the information security budget
- C. Evaluating and reporting the degree of integration
- D. Defining metrics to demonstrate alignment

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 570

Which of the following is a PRIMARY responsibility of an information security governance committee?

- A. Approving the purchase of information security technologies
- B. Approving the information security awareness training strategy
- C. Reviewing the information security strategy
- D. Analyzing information security policy compliance reviews

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 571

What is the MOST effective way to ensure security policies and procedures are up-to-date?

- A. Verify security requirements are being identified and consistently applied.
- B. Align the organization's security practices with industry standards and best practice.
- C. Define and document senior management's vision for the direction of the security
- D. Prevent security documentation audit issues from being raised

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 572

Which of the following is the PRIMARY advantage of having an established information security governance framework in place when an organization is adopting emerging technologies?

- A. An emerging technologies strategy would be in place
- B. A cost-benefit analysis process would be easier to perform
- C. An effective security risk management process is established
- D. End-user acceptance of emerging technologies has been established

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 573

From a risk management perspective, which of the following is MOST important to be tracked in continuous monitoring?

- A. Number of prevented attacks
- B. Changes in the threat environment
- C. Changes in user privileges
- D. Number of failed logins

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 574

Which of the following should be the PRIMARY objective of an information security governance framework?

- A. Increase the organization's return on security investment.
- B. Provide a baseline for optimizing the security profile of the organization.
- C. Ensure that users comply with the organization's information security policies.
- D. Demonstrate compliance with industry best practices to external stakeholders.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 575

An organization has developed mature risk management practices that are followed across all departments. What is the MOST effective way for the audit team to leverage this risk management maturity?

- A. Facilitating audit risk identification and evaluation workshops
- B. Implementing risk responses on management's behalf
- C. Providing assurances to management regarding risk
- D. Integrating the risk register for audit planning purposes

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 576

Which of the following findings would be of GREATEST concern to an IS auditor performing an information security audit of critical server log management activities?

- A. Log records can be overwritten before being reviewed.
- B. Logging procedures are insufficiently documented.
- C. Log records are dynamically into different servers.
- D. Logs are monitored using manual processes.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 577

The BEST way to validate whether a malicious act has actually occurred in an application is to review:

- A. segregation of duties
- B. access controls
- C. activity logs
- D. change management logs

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 578

What type of control is being used when an organization publishes standards and procedures for vulnerability management?

- A. Directive

- B. Preventive
- C. Corrective
- D. Detective

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 579

An IS auditor finds that application servers had inconsistent configurations leading to potential security vulnerabilities. Which of the following should the auditor recommend FIRST?

- A. Enforce server baseline standards.
- B. Improve change management processes using a workflow tool.
- C. Hold the application owner accountable for monitoring metrics.
- D. Use a single vendor for the application servers.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 580

Implementing a strong password policy is part of an organization's information security strategy for the year. A business unit believes the strategy may adversely affect a client's adoption of a recently developed mobile application and has decided not to implement the policy. Which of the following would be the information security manager's BEST course of action?

- A. Analyze the risk and impact of not implementing the policy
- B. Develop and implement a password policy for the mobile application
- C. Escalate non-implementation of the policy to senior management
- D. Benchmark with similar mobile applications to identify gaps

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 581

In a multinational organization, local security regulations should be implemented over global security policy because:

- A. global security policies include unnecessary controls for local businesses
- B. business objectives are defined by local business unit managers
- C. requirements of local regulations take precedence
- D. deploying awareness of local regulations is more practical than of global policy

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 582

Which of the following is a step in establishing a security policy?

- A. Developing platform-level security baselines.
- B. Developing configurations parameters for the network.
- C. Implementing a process for developing and maintaining the policy.
- D. Creating a RACI matrix.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 583

A large number of exceptions to an organization's information security standards have been granted after senior management approved a bring your own device (BYOD) program. To address this situation, it is MOST important for the information security manager to:

- A. introduce strong authentication on devices
- B. reject new exception requests
- C. require authorization to wipe lost devices
- D. update the information security policy

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 584

Which of the following is MOST important for the IS auditor to verify when reviewing the development process of a security policy?

- A. Evidence of active involvement of key stakeholders

- B. Output from the enterprise's risk management system
- C. Identification of the control framework
- D. Evidence of management approval

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 585

Which of the following should be the PRIMARY reason to establish a social media policy for all employees?

- A. To publish acceptable messages to be used by employees when posting
- B. To raise awareness and provide guidance about social media risks
- C. To restrict access to social media during business hours to maintain productivity
- D. To prevent negative public social media postings and comments

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 586

An internal IS auditor discovers that a service organization did not notify its customers following a data breach. Which of the following should the auditor do FIRST?

- A. Notify audit management of the finding.
- B. Report the finding to regulatory authorities.
- C. Notify the service organization's customers.
- D. Require the service organization to notify its customers.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 587

A small organization is experiencing rapid growth and plans to create a new information security policy. Which of the following is MOST relevant to creating the policy?

- A. Industry standards
- B. The business impact analysis (BIA)
- C. The business objectives
- D. Previous audit recommendations

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 588

A CEO requests access to corporate documents from a mobile device that does not comply with organizational policy. The information security manager should FIRST:

- A. evaluate the business risk
- B. evaluate a third-party solution
- C. initiate an exception approval process
- D. deploy additional security controls

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 589

Which of the following is MOST important to consider when developing a bring your own device (BYOD) policy?

- A. Supported operating systems
- B. Procedure for accessing the network
- C. Application download restrictions
- D. Remote wipe procedures

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 590

An IT steering committee assists the board of directors to fulfill IT governance duties by:

- A. developing IT policies and procedures for project tracking.

- B. focusing on the supply of IT services and products.
- C. overseeing major projects and IT resource allocation.
- D. implementing the IT strategy.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 591

Which of the following can provide assurance that an IT project has delivered its planned benefits?

- A. User acceptance testing (UAT)
- B. Steering committee approval
- C. Post-implementation review
- D. Quality assurance evaluation

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 592

Which of the following is MOST important when evaluating the retention period for a cloud provider's client data backups?

- A. Cost of data storage
- B. Contractual commitments
- C. Previous audit recommendations
- D. Industry best practice

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 593

Which of the following is MOST important to include in a contract with a software development service provider?

- A. A list of key performance indicators (KPIs)
- B. Ownership of intellectual property
- C. Service level agreement (SLA)
- D. Explicit contract termination requirements

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 594

Which of the following is a distinguishing feature at the highest level of a maturity model?

- A. There are formal standards and procedures.
- B. Projects are controlled with management supervision.
- C. A continuous improvement process is applied.
- D. Processes are monitored continuously.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 595

The PRIMARY purpose of a precedence diagramming method in managing IT projects is to:

- A. monitor project scope creep.
- B. identify the critical path.
- C. identify key milestones.
- D. minimize delays and overruns.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 596

Reports to the executive level concerning IT performance should focus on:

- A. third-party compliance with organizational practices.
- B. IT performance in relation to operational improvements.
- C. IT deliverables against organizational strategies.
- D. capacity planning effectiveness within the organization.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 597

To enable the alignment of IT staff development plans with IT strategy, which of the following should be done FIRST?

- A. Include strategic objectives in IT staff performance objectives.
- B. Review IT staff job descriptions for alignment.
- C. Identify required IT skill sets that support key business processes.
- D. Develop quarterly training for each IT staff member.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 598

Which of the following should be the PRIMARY basis for planning and prioritizing IT infrastructure security audits?

- A. Asset value to the organization
- B. Management requests
- C. The organization's risk appetite
- D. Security best practice

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 599

Which of the following is the MOST effective control to reduce the risk of information leakage through social media?

- A. Use of keystroke loggers
- B. Periodic review of the data classification policy
- C. Limited access to social media sites in the workplace
- D. Security awareness training

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 600

An operations manager has recently moved to internal audit. Which of the following would be of GREATEST concern when assigning audit projects to this individual?

- A. A control within the audit scope was implemented by the operations manager six months ago.
- B. A control within the audit scope was downgraded to low risk by the operations manager six months ago.
- C. The owner of a process within the audit scope worked for the operations manager six month ago.
- D. A system within the audit scope is supported by an emerging technology for which the operations manager lacks experience.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 601

When developing metrics to measure the contribution of IT to the achievement of business goals, the MOST important consideration is that the metrics:

- A. measure the effectiveness of IT controls in the achievement of IT strategy.
- B. provide quantitative measurement of IT initiatives in relation with business targets.
- C. are expressed in terms of how IT risk impacts the achievement of business goals.
- D. are used by similar industries to measure the effect of IT on business strategy.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 602

The performance, risks, and capabilities of an IT infrastructure are BEST measured using a:

- A. balanced scorecard.
- B. risk management review.
- C. service level agreement (SLA).
- D. control self-assessment (CSA).

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 603

Which of the following is the PRIMARY risk when business units procure IT assets without IT involvement?

- A. Corporate procurement standards are not followed.
- B. The business units want IT to be responsible for maintenance costs.
- C. Data security requirements are not considered.
- D. System inventory becomes inaccurate.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 604

Which of the following would be MOST important to update once a decision has been made to outsource a critical application to a cloud service provider?

- A. Project portfolio
- B. IT resource plan
- C. IT budget
- D. Business impact analysis (BIA)

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 605

Communicating which of the following would BEST encourage management to initiate appropriate actions following the receipt of report findings?

- A. Risk implications of the observations
- B. Strict deadlines to close all observations
- C. Statistical sampling used to derive observations
- D. Recommendations that align with the business strategy

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 606

Which of the following is the BEST key performance indicator (KPI) for determining how well the IT policy is aligned to the business requirements?

- A. Number of approved exceptions to the policy
- B. Total cost of policy breaches
- C. Total cost to support the policy
- D. Number of inquiries regarding the policy

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 607

What is the BEST method to determine if IT resource spending is aligned with planned project spending?

- A. Earned value analysis (EVA)
- B. Gantt chart
- C. Return on investment (ROI) analysis
- D. Critical path analysis

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 608

An external audit team is deciding whether to rely on internal audit's work for an annual compliance audit. Which of the following is the GREATEST consideration when making this decision?

- A. Independence of the internal audit department from management's influence
- B. Professional certifications held by the internal audit team members
- C. Years of experience each of the internal auditors have in performing compliance audits
- D. The level of documentation maintained by internal audit and the methods used to collect evidence

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 609

Which of the following methods would BEST ensure that IT strategy is in line with business strategy?

- A. Break-even analysis
- B. Value analysis
- C. Critical path analysis
- D. Business impact analysis (BIA)

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 610

An information systems security officer's PRIMARY responsibility for business process applications is to:

- A. create role-based rules for each business process.
- B. ensure access rules agree with policies.
- C. authorize secured emergency access.
- D. approve the organization's security policy.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 611

An objective of capacity management is to ensure that:

- A. organizational resources are used efficiently.
- B. available resources are fully utilized.
- C. new resources are allocated for new applications.
- D. resource utilization does not drop below 85%.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 612

An information security team has discovered that users are sharing a login account to an application with sensitive information, in violation of the access policy. Business management indicates that the practice creates operational efficiencies. The information security manager's BEST course of action should be to:

- A. modify the policy
- B. present the risk to senior management
- C. enforce the policy
- D. create an exception for the deviation

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 613

A policy has been established requiring users to install mobile device management (MDM) software on their personal devices. Which of the following would BEST mitigate the risk created by noncompliance with this policy?

- A. Issuing warnings and documenting noncompliance
- B. Disabling remote access from the mobile device
- C. Issuing company-configured mobile devices
- D. Requiring users to sign-off on terms and conditions

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 614

To address the issue that performance pressures on IT may conflict with information security controls, it is MOST important that:

- A. the security policy is changed to accommodate IT performance pressure
- B. noncompliance issues are reported senior management
- C. senior management provides guidance and dispute resolution
- D. information security management understands business performance issues

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 615

The objectives of business process improvement should PRIMARILY include:

- A. minimal impact on staff
- B. incremental changes in productivity
- C. changes of organizational boundaries
- D. performance optimization

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 616

During a review of the IT strategic plan, an IS auditor finds several IT initiatives focused on delivering new systems and technology are not aligned with the organization's strategy. Which of the following would be the IS auditor's BEST recommendation?

- A. Reassess the return on investment for the IT initiatives
- B. Modify IT initiatives that do not map to business strategies
- C. Utilize a balanced scorecard to align IT initiatives to business strategies
- D. Reassess IT initiatives that do not map business strategies

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 617

An organization has outsourced some of its subprocesses to a service provider. When scoping the audit of the provider, the organization's internal auditor should FIRST:

- A. evaluate operational controls of the provider
- B. discuss audit objectives with the provider
- C. review internal audit reports of the provider
- D. review the contract with the provider

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 618

An organization was severely impacted after an advanced persistent threat (APT) attack. Afterwards, it was found that the initial breach happened a month prior to the attack. Management's GREATEST concern should be:

- A. results of the past internal penetration test
- B. the effectiveness of monitoring processes
- C. the installation of critical security patches
- D. external firewall policies

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 619

Software quality assurance (QA) reviews are planned as part of system development. At which stage in the development process should the first review be initiated?

- A. At pre-implementation planning
- B. As a part of the user requirements definition
- C. Immediately prior to user acceptance testing
- D. During the feasibility study

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 620

An organization has made a strategic decision to split into separate operating entities to improve profitability. However, the IT infrastructure remains shared between the entities. Which of the following would BEST help to ensure that IS audit still covers key risk areas within the IT environment as part of its annual plan?

- A. Increasing the frequency of risk-based IS audits for each business entity
- B. Revising IS audit plans to focus on IT changes introduced after the split
- C. Conducting an audit of newly introduced IT policies and procedures
- D. Developing a risk-based plan considering each entity's business processes

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 621

An IS auditor determines that an online retailer processing credit card information does not have a data classification process. The auditor's NEXT step should be to:

- A. recommend encryption of all sensitive data at rest
- B. determine existing controls around sensitive data
- C. recommend the implementation of data loss prevention (DLP) tools
- D. inquire if there have been any data loss incidents

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 622

An IS auditor is reviewing an organization's network vulnerability scan results. Which of the following processes would the scan results MOST likely feed into?

- A. Firewall maintenance
- B. Patch management
- C. Incident response
- D. Traffic management

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 623

Which of the following is MOST critical for the effective implementation of IT governance?

- A. Internal auditor commitment
- B. Supportive corporate culture
- C. Strong risk management practices
- D. Documented policies

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 624

When auditing the IT governance of an organization planning to outsource a critical financial application to a cloud vendor, the MOST important consideration for the auditor should be:

- A. the cost of the outsourced system.
- B. the inclusion of a service termination clause.
- C. alignment with industry standards.
- D. alignment with business requirements.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 625

An IS auditor has completed a review of an outsourcing agreement and has identified IT governance issues. Which of the following is the MOST effective and efficient way of communicating the issues at a meeting with senior management?

- A. Present a completed report and discuss the details.
- B. Provide a detailed report in advance and open the floor to questions.
- C. Present an overview highlighting the key findings.
- D. Provide a plan of action and milestones.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 626

An information security manager's PRIMARY objective for presenting key risks to the board of directors is to:

- A. re-evaluate the risk appetite.
- B. quantify reputational risks.
- C. meet information security compliance requirements.
- D. ensure appropriate information security governance.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 627

Which of the following is the MOST effective way of ensuring that business units comply with an information security governance framework?

- A. Conducting information security awareness training
- B. Performing security assessments and gap analyses
- C. Integrating security requirements with processes
- D. Conducting a business impact analysis (BIA)

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 628

Which of the following is MOST important to the successful implementation of an information security governance framework across the organization?

- A. The existing organizational security culture
- B. Security management processes aligned with security objectives
- C. Organizational security controls deployed in line with regulations
- D. Security policies that adhere to industry best practices

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 629

After implementing an information security governance framework, which of the following would provide the BEST information to develop an information security project plan?

- A. Balanced scorecard
- B. Recent audit results
- C. Risk heat map
- D. Gap analysis

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 630

Which of the following is the MOST effective way to achieve the integration of information security governance into corporate governance?

- A. Ensure information security aligns with IT strategy.
- B. Provide periodic IT balanced scorecards to senior management.
- C. Align information security budget requests to organizational goals.
- D. Ensure information security efforts support business goals.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 631

Within a security governance framework, which of the following is the MOST important characteristic of the information security committee? The committee:

- A. conducts frequent reviews of the security policy.
- B. includes a mix of members from all levels of management.
- C. has a clearly defined charter and meeting protocols.
- D. has established relationships with external professionals.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 632

The PRIMARY purpose of aligning information security with corporate governance objectives is to:

- A. identify an organization's tolerance for risk.
- B. re-align roles and responsibilities.
- C. build capabilities to improve security processes.
- D. consistently manage significant areas of risk.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 633

In an organization where IT is critical to its business strategy and where there is a high level of operational dependence on IT, senior management commitment to security is BEST demonstrated by the:

- A. reporting line of the chief information security officer (CISO).
- B. segregation of duties policy.
- C. existence of an IT steering committee.
- D. size of the IT security function.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 634

Which of the following would be MOST effective when justifying the cost of adding security controls to an existing web application?

- A. Vulnerability assessment results
- B. Application security policy
- C. A business case
- D. Internal audit reports

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 635

In the absence of technical controls, what would be the BEST way to reduce unauthorized text messaging on company-supplied mobile devices?

- A. Update the corporate mobile usage policy to prohibit texting.
- B. Conduct a business impact analysis (BIA) and provide the report to management.
- C. Stop providing mobile devices until the organization is able to implement controls.
- D. Include the topic of prohibited texting in security awareness training.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 636

A large organization is considering a policy that would allow employees to bring their own smartphones into the organizational environment. The MOST important concern to the information security manager should be the:

- A. lack of a device management solution.
- B. decrease in end user productivity.
- C. impact on network capacity.
- D. higher costs in supporting end users.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 637

Which of the following is the BEST way to demonstrate to senior management that organizational security practices comply with industry standards?

- A. A report on the maturity of controls
- B. Up-to-date policy and procedures documentation
- C. Existence of an industry-accepted framework
- D. Results of an independent assessment

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 638

An information security manager learns that a departmental system is out of compliance with the information security policy's authentication requirements. Which of the following should be the information security manager's FIRST course of action?

- A. Isolate the noncompliant system from the rest of the network.
- B. Submit the issue to the steering committee for escalation.
- C. Request risk acceptance from senior management.
- D. Conduct an impact analysis to quantify the associated risk.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 639

Following significant organizational changes, which of the following is the MOST important consideration when updating the IT policy?

- A. The policy is integrated into job descriptions.
- B. The policy is endorsed by senior executives.
- C. The policy is compliant with relevant laws and regulations.
- D. The policy is aligned with industry standards and best practice.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 640
Which of the following is the FIRST consideration when developing a data retention policy?

- A. Determining the backup cycle based on retention period
- B. Designing an infrastructure storage strategy
- C. Identifying the legal and contractual retention period for data
- D. Determining the security access privileges to the data

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 641
Which of the following factors will BEST promote effective information security management?

- A. Senior management commitment
- B. Identification and risk assessment of sensitive resources
- C. Security awareness training
- D. Security policy framework

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 642
A review of Internet security disclosed that users have individual user accounts with the Internet service providers (ISPs) and use these accounts for downloading business data. The organization wants to ensure that only corporate network is used. The organization should FIRST:

- A. use a proxy server to filter out Internet sites that should not be accessed.
- B. keep a manual log of Internal access.
- C. monitor remote access activities.
- D. include a statement in its security policy about Internet use.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 643
Which of the following BEST indicates a need to review an organization's information security policy?

- A. Completion of annual IT risk assessment
- B. Increasing complexity of business transactions
- C. Increasing exceptions approved by management
- D. High number of low-risk findings in the audit report

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 644
Which of the following is a directive control?

- A. Establishing an information security operations team
- B. Updating data loss prevention software
- C. Implementing an information security policy
- D. Configuring data encryption software

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 645
An organization's IT security policy requires annual security awareness training for all employees. Which of the following would provide the BEST evidence of the training's effectiveness?

- A. Results of a social engineering test

- B. Interviews with employees
- C. Decreased calls to the incident response team
- D. Surveys completed by randomly selected employees

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 646
Which type of risk would MOST influence the selection of a sampling methodology?

- A. Control
- B. Inherent
- C. Residual
- D. Detection

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 647
Which of the following is the MOST effective control to mitigate unintentional misuse of authorized access?

- A. Regular monitoring of user access logs
- B. Annual sign-off of acceptable use policy
- C. Security awareness training
- D. Formalized disciplinary action

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 648
Which of the following will BEST protect an organization against spear phishing?

- A. Email content filtering
- B. Acceptable use policy
- C. End-user training
- D. Antivirus software

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 649
Which of the following is MOST likely to be included in an enterprise information security policy?

- A. Password composition requirements
- B. Consequences of noncompliance
- C. Audit trail review requirements
- D. Security monitoring strategy

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 650
Which of the following processes is the FIRST step in establishing an information security policy?

- A. Security controls evaluation
- B. Business risk assessment
- C. Review of current global standards
- D. Information security audit

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 651
A business unit uses an e-commerce application with a strong password policy. Many customers complain that they cannot remember their passwords because they are too long and complex. The business unit states it is imperative to improve the customer experience. The information security manager should FIRST:

- A. change the password policy to improve the customer experience.
- B. recommend implementing two-factor authentication.
- C. research alternative secure methods of identity verification.

D. evaluate the impact of the customer's experience on business revenue.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 652

The GREATEST benefit of using a maturity model when providing security reports to management is that it presents the:

- A. current and target security state for the business.
- B. security program priorities to achieve an accepted risk level.
- C. assessed level of security risk at a particular point in time.
- D. level of compliance with internal policy.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 653

A cloud service provider is unable to provide an independent assessment of controls. Which of the following is the BEST way to obtain assurance that the provider can adequately protect the organization's information?

- A. Check references supplied by the provider's other customers.
- B. Invoke the right to audit per the contract.
- C. Review the provider's information security policy.
- D. Review the provider's self-assessment.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 654

Which of the following is MOST likely to result from compliance testing?

- A. Comparison of data with physical counts
- B. Confirmation of data with outside sources
- C. Identification of errors due to processing mistakes
- D. Discovery of controls that have not been applied

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 655

When designing an incident response plan to be agreed upon with a cloud computing vendor, including which of the following will BEST help to ensure the effectiveness of the plan?

- A. A training program for the vendor staff
- B. An audit and compliance program
- C. Responsibility and accountability assignments
- D. Requirements for onsite recovery testing

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 656

Which of the following would BEST help to ensure compliance with an organization's information security requirements by an IT service provider?

- A. Defining the business recovery plan with the IT service provider
- B. Requiring an external security audits of the IT service provider
- C. Defining information security requirements with internal IT
- D. Requiring regular reporting from the IT service provider

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 657

Which of the following should be of MOST influence to an information security manager when developing IT security policies?

- A. Past and current threats
- B. IT security framework
- C. Compliance with regulations
- D. Business strategy

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 658

Which of the following is the BEST approach to identify noncompliance issues with legal, regulatory, and contractual requirements?

- A. Vulnerability assessment
- B. Risk assessment
- C. Business impact analysis (BIA)
- D. Gap analysis

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 659

Which of the following provides the GREATEST assurance that an organization allocates appropriate resources to respond to information security events?

- A. Incident classification procedures
- B. Threat analysis and intelligence reports
- C. An approved IT staffing plan
- D. Information security policies and standards.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 660

Which of the following is MOST useful to include in a report to senior management on a regular basis to demonstrate the effectiveness of the information security program?

- A. Critical success factors (CSFs)
- B. Key risk indicators (KRIs)
- C. Capability maturity models
- D. Key performance indicators (KPIs)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 661

When the inherent risk of a business activity is lower than the acceptable risk level, the BEST course of action would be to:

- A. implement controls to mitigate the risk.
- B. report compliance to management.
- C. review the residual risk level.
- D. monitor for business changes.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 662

Over the last year, an information security manager has performed risk assessments on multiple third-party vendors. Which of the following criteria would be MOST helpful in determining the associated level of risk applied to each vendor?

- A. Compensating controls in place to protect information security
- B. Corresponding breaches associated with each vendor
- C. Criticality of the service to the organization
- D. Compliance requirements associated with the regulation

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 663

An information security manager is concerned that executive management does not support information security initiatives. Which of the following is the BEST way to address this situation?

- A. Demonstrate alignment of the information security function with business needs.
- B. Escalate noncompliance concerns to the internal audit manager.
- C. Report the risk and status of the information security program to the board.
- D. Revise the information security strategy to meet executive management's expectations.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 664

The MOST important reason that security risk assessment should be conducted frequently throughout an organization is because:

- A. threats to the organization may change.
- B. controls should be regularly tested.
- C. compliance with legal and regulatory standards should be reassessed.
- D. control effectiveness may weaken.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 665

Which of the following is the MOST important factor to consider when establishing a severity hierarchy for information security incidents?

- A. Management support
- B. Business impact
- C. Regulatory compliance
- D. Residual risk

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 666

The PRIMARY reason an organization would require that users sign an acknowledgment of their system access responsibilities is to:

- A. maintain compliance with industry best practices.
- B. serve as evidence of security awareness training.
- C. assign accountability for transactions made with the user's ID.
- D. maintain an accurate record of users' access rights.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 667

Which of the following would provide the MOST reliable evidence to indicate whether employee access has been deactivated in a timely manner following termination?

- A. Comparing termination forms with dates in the HR system
- B. Reviewing hardware return-of-asset forms
- C. Interviewing supervisors to verify employee data is being updated immediately
- D. Comparing termination forms with system transaction log entries

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 668

To effectively classify data, which of the following MUST be determined?

- A. Data controls
- B. Data ownership
- C. Data users
- D. Data volume

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 669

Which of the following is the MOST effective way to ensure security policies are relevant to organizational business practices?

- A. Leverage security steering committee contribution.
- B. Obtain senior management sign-off.
- C. Integrate industry best practices.
- D. Conduct an organization-wide security audit.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 670

To integrate security into system development life cycle (SDLC) processes, an organization MUST ensure that security:

- A. is a prerequisite for completion of major phases.
- B. performance metrics have been met.
- C. roles and responsibilities have been defined.
- D. is represented on the configuration control board.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 671

Which of the following is the PRIMARY role of a data custodian?

- A. Processing information
- B. Securing information
- C. Classifying information
- D. Validating information

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 672

The PRIMARY focus of a training curriculum for members of an incident response team should be:

- A. technology training.
- B. security awareness.
- C. external corporate communication.
- D. specific role training.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 673

Which of the following should be the PRIMARY objective of the information security incident response process?

- A. Minimizing negative impact to critical operations
- B. Communicating with internal and external parties
- C. Classifying incidents
- D. Conducting incident triage

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 674

Which of the following is MOST important to include in a contract with a critical service provider to help ensure alignment with the organization's information security program?

- A. Escalation paths
- B. Right-to-audit clause
- C. Termination language
- D. Key performance indicators (KPIs)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 675

Which of the following is MOST important when selecting an information security metric?

- A. Defining the metric in quantitative terms
- B. Aligning the metric to the IT strategy
- C. Defining the metric in qualitative terms
- D. Ensuring the metric is repeatable

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 676

The PRIMARY purpose of asset valuation for the management of information security is to:

- A. eliminate the least significant assets.
- B. provide a basis for asset classification.
- C. determine the value of each asset.
- D. prioritize risk management activities.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 677

Which of the following is MOST effective in the strategic alignment of security initiatives?

- A. A security steering committee is set up within the IT department.
- B. Key information security policies are updated on a regular basis.
- C. Business leaders participate in information security decision making.
- D. Policies are created with input from business unit managers.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 678

Which of the following is the BEST approach for determining the maturity level of an information security program?

- A. Review internal audit results.
- B. Engage a third-party review.
- C. Perform a self-assessment.
- D. Evaluate key performance indicators (KPIs).

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 679

An organization with a maturing incident response program conducts post-incident reviews for all major information security incidents. The PRIMARY goal of these reviews should be to:

- A. identify security program gaps or systemic weaknesses that need correction.
- B. prepare properly vetted notifications regarding the incidents to external parties.
- C. identify who should be held accountable for the security incidents.
- D. document and report the root cause of the incidents for senior management.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 680

To gain a clear understanding of the impact that a new regulatory requirement will have on an organization's information security controls, an information security manager should FIRST:

- A. conduct a risk assessment.
- B. perform a gap analysis.
- C. conduct a cost-benefit analysis.
- D. interview senior management.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 681

Which of the following is the PRIMARY purpose of conducting a business impact analysis (BIA)?

- A. Identifying risk mitigation options
- B. Identifying key business risks
- C. Identifying critical business processes
- D. Identifying the threat environment

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 682

Which of the following would BEST assist an information security manager in gaining strategic support from executive management?

- A. Research on trends in global information security breaches
- B. Risk analysis specific to the organization
- C. Annual report of security incidents within the organization
- D. Rating of the organization's security based on international standards

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 683

An information security manager has developed a strategy to address new information security risks resulting from recent changes in the business. Which of the following would be MOST important to include when presenting the strategy to senior management?

- A. The impact of organizational changes on the security risk profile
- B. The costs associated with business process changes
- C. Results of benchmarking against industry peers
- D. Security controls needed for risk mitigation

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 684

Which of the following is the BEST way for an information security manager to justify continued investment in the information security program when the organization is facing significant budget cuts?

- A. Demonstrate an increase in ransomware attacks targeting peer organizations.
- B. Demonstrate the readiness of business continuity plans.
- C. Demonstrate that implemented program controls are effective.
- D. Demonstrate that the program enables business activities.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 685

Which of the following is MOST important to ensure when planning a black box penetration test?

- A. The test results will be documented and communicated to management.
- B. Diagrams of the organization's network architecture are available.
- C. The environment and penetration test scope have been determined.
- D. The management of the client organization is aware of the testing.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 686

Which of the following human resources management practices BEST leads to the detection of fraudulent activity?

- A. Background checks
- B. Time reporting
- C. Employee code of ethics
- D. Mandatory time off

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 687

Which of the following would BEST enable alignment of IT with business objectives?

- A. Leveraging an IT framework
- B. Completing an IT risk assessment
- C. Adopting industry best practices
- D. Monitoring key performance indicators (KPIs)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 688

Which of the following is the FIRST step when conducting a business impact analysis (BIA)?

- A. Identifying critical information resources
- B. Identifying events impacting continuity of operations
- C. Analyzing past transaction volumes
- D. Creating a data classification scheme

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 689

Which of the following findings would have the GREATEST impact on the objective of a business intelligence system?

- A. Key control have not been tested in a year.
- B. Decision support queries use database functions proprietary to the vendor.
- C. The hot site for disaster recovery does not include the decision support system.
- D. Management reports have not been evaluated since implementation.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 690

When reviewing an organization's IT governance processes, which of the following provides the BEST indication that information security expectations are being met at all levels?

- A. Achievement of established security metrics
- B. Approval of the security program by senior management
- C. Utilization of an internationally recognized security standard
- D. Implementation of a comprehensive security awareness program

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 691

Which of the following is the MOST important benefit of involving IS audit when implementing governance of enterprise IT?

- A. Identifying relevant roles for an enterprise IT governance framework
- B. Verifying that legal, regulatory and contractual requirements are being met
- C. Making decisions regarding risk response and monitoring of residual risk
- D. Providing independent and objective feedback to facilitate improvement of IT processes

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 692

Which of the following is the MOST appropriate action to formalize IT governance in an organization?

- A. Evaluating the IT strategy
- B. Modifying IT goals and strategy
- C. Establishing an IT steering committee
- D. Implementing risk management

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 693

Which of the following is MOST important for an IS auditor to consider during a review of the IT governance of an organization?

- A. Funding allocations
- B. Risk management methodology
- C. Defined service levels
- D. Decision making responsibilities

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 694

Which of the following findings should be of MOST concern to an IS auditor when evaluating information security governance within an organization?

- A. The data center manager has final sign-off on security projects.
- B. The information security oversight committee meets quarterly.

- C. The information security department has difficulty filling vacancies.
- D. Information security policies were last updated two years ago.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 695

When reviewing business continuity plan (BCP) test results, it is MOST important for the IS auditor to determine whether the test:

- A. verifies the ability to resume key business operations.
- B. considers changes to the systems environment.
- C. assesses the capability to retrieve vital records.
- D. follows up on activities that occurred since the previous test.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 696

While reviewing an organization's business continuity plan (BCP), an IS auditor observes that a recently developed application is not included. The IS auditor should:

- A. ensure that the criticality of the application is determined.
- B. ignore the observation as the application is not mission critical.
- C. include in the audit findings that the BCP is incomplete.
- D. recommend that the application be incorporated in the BCP.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 697

The BEST method an organization can employ to align its business continuity plan (BCP) and disaster recovery plan (DRP) with core business needs is to:

- A. execute periodic walk-throughs of the plans.
- B. update the business impact analysis (BIA) for significant business changes.
- C. outsource the maintenance of the BCP and DRP to a third party.
- D. include BCP and DRP responsibilities as a part of new employee training.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 698

When preparing to evaluate the effectiveness of an organization's IT strategy, an IS auditor should FIRST review:

- A. information security procedures.
- B. the IT governance framework.
- C. the most recent audit results.
- D. IT processes and procedures.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 699

Which of the following is the GREATEST advantage of using a framework to guide an organization's governance of IT?

- A. It enables consistency when making strategic IT investments across the organization.
- B. It enables better management of the annual IT budget provided by the board of directors.
- C. It enables improvements to the security of high-risk systems in the organization.
- D. It enables the achievement of service levels between IT and true business departments.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 700

Which of the following observations should be of GREATEST concern to an IS auditor performing a review of an organization's IT governance structure?

- A. The chief risk officer is also the chief information officer.
- B. The chief information officer is prohibited from making capital decisions regarding IT.
- C. The IT steering committee has oversight of the IT budget.
- D. There are no IT subject matter experts on the board of directors.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 701

An organization recently implemented an industry-recognized IT framework to improve the overall effectiveness of IT governance. Which of the following would BEST enable an IS auditor to access the implementation against the framework?

- A. Capability maturity model
- B. Key risk indicators (KRIs)
- C. Industry benchmarking
- D. Balanced scorecard

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 702

An organization plans to allow third parties to collect customer personal data from a retail loyalty platform via an application programming interface (API). Which of the following should be the PRIMARY consideration when designing this API?

- A. Data governance policies
- B. System resilience
- C. Regulatory compliance
- D. Data availability

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 703

Which of the following would provide management with the MOST reasonable assurance that a new data warehouse will meet the needs of the organization?

- A. Appointing data stewards to provide effective data governance
- B. Classifying data quality issues by the severity of their impact to the organization
- C. Integrating data requirements into the system development life cycle (SDLC)
- D. Facilitating effective communication between management and developers

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 704

Which of the following has the GREATEST influence on the success of IT governance?

- A. IT strategy is embedded in all risk management processes
- B. Alignment of IT strategies with the entity's vision
- C. The CIO is a member of the audit committee
- D. Clear, concise, and enforced IS policies

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 705

Which of the following is the MOST important step in the development of an effective IT governance action plan?

- A. Conducting a business impact analysis (BIA)
- B. Preparing a statement of sensitivity
- C. Setting up an IT governance framework for the process
- D. Measuring IT governance key performance indicators (KPIs)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 706

Which of the following governance functions is responsible for ensuring IT projects have sufficient resources and are prioritized appropriately?

- A. Board of directors
- B. IT management
- C. IT steering committee
- D. Executive management

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 707

Which of the following is a benefit of requiring management to issue a report to stakeholders regarding the internal controls over IT?

- A. Transparency of IT costs
- B. Improved portfolio management
- C. Improved cost management
- D. Focus on IT governance

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 708

An IS auditor's role in privacy and security is to:

- A. assist in developing an IS security strategy.
- B. verify compliance with applicable laws.
- C. implement risk management methodologies.
- D. assist the governance steering committee with implementing a security policy.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 709

Which of the following should be of GREATEST concern to an IS auditor reviewing an organization's initiative to adopt an enterprise governance framework?

- A. The organization has not identified the business drivers for adopting the framework.
- B. The organization's security department has not been involved with the initiative.
- C. The organization has tried to adopt the entire framework at once.
- D. The organization has not provided employees with formal training on the framework.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 710

Which of the following IT processes is likely to have the GREATEST inherent regulatory risk?

- A. IT project management
- B. Data management
- C. Capacity management
- D. IT resource management

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 711

Which of the following is the BEST indication that an organization has achieved legal and regulatory compliance?

- A. The board of directors and senior management accept responsibility for compliance.
- B. An independent consultant has been appointed to ensure legal and regulatory compliance.
- C. Periodic external and internal audits have not identified instances of noncompliance.
- D. The risk management process incorporates noncompliance as a risk.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 712

Which of the following is the MOST significant obstacle to establishing a new privacy program?

- A. Unresolved overlap of security and privacy roles and responsibilities
- B. An insufficient privacy awareness training program
- C. A Complex legal and regulatory landscape
- D. Failure to perform a business impact analysis (BIA)

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 713

Which of the following is the BEST evidence that an organization is aware of applicable laws and regulations?

- A. The organization's compliance matrix
- B. History of legal actions and regulatory correspondence
- C. The existence of an employee awareness training program
- D. Industry benchmark results

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 714

Which of the following is MOST important to consider when reviewing a third-party service agreement for disaster recovery services?

- A. Recovery point objectives (RPOs) and recovery time objectives (RTOs) are included in the agreement.
- B. The lowest price possible is obtained for the service rendered.
- C. Security and regulatory requirements are addressed in the agreement.
- D. Provisions exist to retain ownership of intellectual property in the event of termination.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 715

A new regulatory standard in one country of a global organization has recently prohibited cross-border transfer of personal data. An IS auditor has been asked to determine the organization's level of exposure in the affected country. Which of the following would be MOST helpful in making this assessment?

- A. Identifying data security threats in the affected jurisdiction
- B. Reviewing data classification procedures associated with the affected jurisdiction
- C. Identifying business processes associated with personal data exchange with the affected jurisdiction
- D. Developing an inventory of all business entities that exchange personal data with the affected jurisdiction

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 716

A new regulatory standard for data privacy requires an organization to protect personally identifiable information (PII). Which of the following is MOST important to include in the audit engagement plan to access compliance with the new standard?

- A. Identification of IT systems that host PII
- B. Review of data loss risk scenarios
- C. Identification of unencrypted PII
- D. Review of data protection procedures

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 717

Which of the following tests would provide the BEST assurance that a health care organization is handling patient data appropriately?

- A. Compliance with local laws and regulations
- B. Compliance with the organization's policies and procedures
- C. Compliance with action plans resulting from recent audits
- D. Compliance with industry standards and best practice

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 718

Which of the following is the BEST source of information for an IS auditor to use as a baseline to assess the adequacy of an organization's privacy policy?

- A. Benchmark studies of similar organizations
- B. Local privacy standards and regulations
- C. Historical privacy breaches and related root causes
- D. Globally accepted privacy best practices

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 719

An IS auditor is reviewing standards and compliance requirements related to an upcoming systems audit. The auditor notes that the industry standards are less stringent than local regulatory standards. How should the auditor proceed?

- A. Audit to the standards with the highest requirements.
- B. Audit exclusively to the industry standards.
- C. Coordinate with regulatory officers to determine necessary requirements.
- D. Audit to the policies and procedures of the organization.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 720

A new regulation requires organizations to report significant security incidents to the regulator within 24 hours of identification. Which of the following is the IS auditor's BEST recommendation to facilitate compliance with the regulation?

- A. Include the requirement in the incident management response plan.
- B. Establish key performance indicators (KPIs) for timely identification of security incidents.
- C. Enhance the alert functionality of the intrusion detection system (IDS).
- D. Engage an external security incident response expert for incident handling.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 721

Following an acquisition, it was decided that legacy applications subject to compliance requirements will continue to be used until they can be phased out. The IS auditor needs to determine where there are control redundancies and where gaps may exist. Which of the following activities would be MOST helpful in making this determination?

- A. Control self-assessments
- B. Risk assessment
- C. Control testing
- D. Control mapping

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 722

A region where an organization conducts business has announced changes in privacy legislation. Which of the following should an IS auditor do FIRST to prepare for the changes?

- A. Perform a gap analysis with current privacy procedures.
- B. Provide suggested updates to the organization's privacy procedures.
- C. Communicate the changes in privacy legislation to the legal department.
- D. Design compensating controls to be in compliance with new privacy legislation.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 723

Which of the following is the MOST effective way for an IS auditor to identify unauthorized changes to the production state of a critical business application?

- A. Run an automated scan of the production environment to detect missing software patches.
- B. Compare a list of production system changes with the configuration management database (CMDB).
- C. Review recently approved changes to application programming interfaces (API) in the production environment.
- D. Review recent updates in the configuration management database (CMDB) for compliance with IT policies.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 724

When creating a new risk management program, it is CRITICAL to consider:

- A. the risk appetite.
- B. compliance measures.
- C. risk mitigation techniques.
- D. resource utilization.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 725

Which of the following is the BEST way to increase end-user compliance with information security policies?

- A. Regular awareness training
- B. Periodic audit and review
- C. Use of monitoring software
- D. Establishing a whistle-blower policy

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 726

An audit report that specifies responsibility for the closure of noncompliance issues is BEST enhanced by including:

- A. detailed mitigating steps.
- B. a list of audit staff who will oversee remediation.
- C. cost estimates for remediation.
- D. target dates for remediation.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 727

An IS auditor is assigned to review the IS department's quality procedures. Upon contacting the IS manager, the auditor finds that there is an informal unwritten set of standards. Which of the following should be the auditor's NEXT action?

- A. Finalize the audit and report the finding.
- B. Make recommendations to IS management as to appropriate quality standards.
- C. Postpone the audit until IS management implements written standards.
- D. Document and test compliance with the informal standards.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 728

Which function in the purchasing module of an enterprise resource planning (ERP) system ensures payments are not issued for incorrect invoices?

- A. Sequential payment numbers
- B. Three-way match
- C. Purchasing authority levels
- D. Management workflow approval

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 729

Which of the following is the BEST way for an IT forensics investigator to detect evidence of steganography?

- A. Compare file hashes between original and modified image files.
- B. Identify and analyze emergent properties within a file system's metadata.
- C. Recover deleted files from a suspected hard drive utilizing forensics software.
- D. Scan computer operating systems using administrative tools.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 730

Which of the following controls MOST efficiently ensures that orders transmitted from a sales office to a production warehouse are received accurately and completely?

- A. Transaction totals and record counts should be sent and reconciled before transaction processing.
- B. Parity checking should be incorporated into all data transmissions.
- C. Data should be sent back to the originating site and compared to what was sent to production.
- D. Continuity of numerical sequences for all sales orders should be checked.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 731

Which of the following should an IS auditor use when verifying a three-way match has occurred in an enterprise resource planning (ERP) system?

- A. Goods delivery notification
- B. Purchase requisition
- C. Bank confirmation
- D. Purchase order

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 732

Which of the following poses the GREATEST risk to the enforceability of networking policies in a virtualized environment?

- A. Transmission of data on public networks
- B. Lack of encryption for data at rest
- C. Use of a public key infrastructure
- D. Lack of visibility into the networks

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 733

Which of the following is MOST helpful when establishing the authenticity of digital evidence collected from a hard disk?

- A. Bit-by-bit image of the hard disk
- B. Hash of the files on the hard disk
- C. Chain of custody documentation
- D. Confirmation by witnesses

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 734

Which of the following is the MOST efficient solution for a multi-location healthcare organization that wants to be able to access patient data wherever patients present themselves for care?

- A. Network segmentation
- B. Software as a Service (SaaS) provider
- C. Dynamic localization
- D. Infrastructure as a Service (IaaS) provider

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 735

The IS department is evaluated monthly on its cost-revenue ratio, user satisfaction rate, and computer downtime. This can BEST be characterized as an application of:

- A. control self-assessment (CSA).
- B. balanced scorecard.
- C. value chain analysis.
- D. risk control framework.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 736

What is the BEST way to control updates to the vendor master file in an accounts payable system?

- A. Using prenumbered and authorized request forms
- B. Having only one person updating the master file
- C. Periodically reviewing the entire vendor master file
- D. Comparing updates against authorization

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 737

During an investigation of transactions in a core banking system, fraudulent transactions are discovered that will require the involvement of law enforcement. Which of the following should be done FIRST?

- A. Ensure evidence is preserved.
- B. Initiate incident response procedures.
- C. Evaluate the business impact.
- D. Notify internal audit management.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 738

An organization has outsourced its data processing function to a service provider. Which of the following would BEST determine whether the service provider continues to meet the organization's objectives?

- A. Periodic audits of controls by an independent auditor
- B. Adequacy of the service provider's insurance
- C. Assessment of the personnel training processes of the provider
- D. Review of performance against service level agreements (SLAs)

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 739

Which of the following would BEST facilitate the successful implementation of an IT-related framework?

- A. Aligning the framework to industry best practices
- B. Involving appropriate business representation within the framework
- C. Establishing committees to support and oversee framework activities
- D. Documenting IT-related policies and procedures

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 740

The MAJOR reason for replacing checks with electronic funds transfer (EFT) systems in the accounts payable area is to:

- A. increase organizational credibility.
- B. decrease the risk of unauthorized changes to payment transactions.
- C. decrease the number of paper-based payment forms.
- D. increase the efficiency of the payment process.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 741

In an environment where most IT services have been outsourced, continuity planning is BEST controlled by:

- A. outsourced service provider management.
- B. business management.
- C. continuity planning specialists.
- D. IT management.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 742

Which of the following is MOST important to include in a business continuity plan (BCP)?

- A. Vendor contact information
- B. Documentation of critical systems
- C. Documentation of data center floor plans
- D. Backup site location information

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 743

An organization wants to test business continuity using a scenario in which there are many remote workers trying to access production data at the same time. Which of the following is the BEST testing method in this situation?

- A. Application failover testing.

- B. Network stress testing.
- C. Alternate site testing.
- D. Network penetration testing.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 744

An IS auditor is performing a business continuity plan (BCP) audit and identifies that the plan has not been tested for five years. However, the plan was successfully activated during a recent extended power outage. Which of the following is the IS auditor's BEST course of action?

- A. Determine if lessons learned from the activation were incorporated into the plan.
- B. Determine if the business impact analysis (BIA) is still accurate.
- C. Determine if a follow-up BCP audit is required to identify future gaps.
- D. Determine if the annual BCP training program is in need of a review.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 745

In assessing the priority given to systems covered in an organization's business continuity plan (BCP), an IS auditor should FIRST:

- A. review results of previous business continuity plan (BCP) tests.
- B. review the backup and restore processes.
- C. verify the criteria for disaster recovery site selection.
- D. validate the recovery time objectives and recovery point objectives.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 746

Which of the following is the MOST important prerequisite for implementing a data loss prevention (DLP) tool?

- A. Identifying where existing data resides and establishing a data classification matrix.
- B. Requiring users to save files in secured folders instead of a company-wide shared drive
- C. Reviewing data transfer logs to determine historical patterns of data flow
- D. Developing a DLP policy and requiring signed acknowledgement by users

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 747

An organization's IT security policy states that user IDs must uniquely identify individuals and that users should not disclose their passwords. An IS auditor discovers that several generic user IDs are being used. Which of the following is the MOST appropriate course of action for the auditor?

- A. Investigate the noncompliance.
- B. Include the finding in the final audit report.
- C. Recommend disciplinary action.
- D. Recommend a change in security policy.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 748

An organization plans to launch a social media presence as part of a new customer service campaign. Which of the following is the MOST significant risk from the perspective of potential litigation?

- A. The policy stating what employees can post on the organization's behalf is unclear.
- B. Access to corporate-sponsored social media accounts requires only single-factor authentication.
- C. Approved employees can use personal devices to post on the company's behalf.
- D. There is a lack of clear procedures for responding to customers on social media outlets.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 749

Which of the following observations noted during a review of the organization's social media practices should be of MOST concern to the IS auditor?

- A. The organization does not require approval for social media posts.

- B. More than one employee is authorized to publish on social media on behalf of the organization.
- C. Not all employees using social media have attended the security awareness program.
- D. The organization does not have a documented social media policy.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 750

An IS auditor is conducting a review of an organization's information systems and discovers data that is no longer needed by business applications. Which of the following would be the IS auditor's BEST recommendation?

- A. Ask the data custodian to remove it after confirmation from the business user.
- B. Assess the data according to the retention policy.
- C. Back up the data to removable media and store in a secure area.
- D. Keep the data and protect it using a data classification policy.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 751

Which of the following provides an IS auditor the MOST assurance that an organization is compliant with legal and regulatory requirements?

- A. The IT manager is responsible for the organization's compliance with legal and regulatory requirements.
- B. Controls associated with legal and regulatory requirements have been identified and tested.
- C. Senior management has provided attestation of legal and regulatory compliance.
- D. There is no history of complaints or fines from regulators regarding noncompliance.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 752

An IS auditor is reviewing IT policies and found that most policies have not been reviewed in over 3 years. The MOST significant risk is that the policies do not reflect:

- A. current legal requirements.
- B. the vision of the CEO.
- C. the mission of the organization.
- D. current industry best practices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 753

Which of the following is MOST important to ensure that electronic evidence collected during a forensic investigation will be admissible in future legal proceedings?

- A. Restricting evidence access to professionally certified forensic investigators
- B. Engaging an independent third party to perform the forensic investigation
- C. Performing investigative procedures on the original hard drives rather than images of the hard drives
- D. Documenting evidence handling by personnel throughout the forensic investigation

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 754

During the planning stage of a compliance audit, an IS auditor discovers that a bank's inventory of compliance requirements does not include recent regulatory changes related to managing data risk. What should the auditor do FIRST?

- A. Discuss potential regulatory issues with the legal department.
- B. Ask management why the regulatory changes have not been included.
- C. Exclude recent regulatory changes from the audit scope.
- D. Report the missing regulatory updates to the chief information officer (CIO).

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 755

Which of the following data would be used when performing a business impact analysis (BIA)?

- A. Projected impact of current business on future business

- B. Cost of regulatory compliance
- C. Cost benefit analysis of running the current business
- D. Expected costs for recovering the business.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 756

An organization has decided to migrate payroll processing to a new platform hosted by a third party in a different country. Which of the following is MOST important for the IS auditor to consider?

- A. The service provider's compliance with privacy regulations
- B. Whether the contract contains a right-to-terminate clause
- C. The service provider's compliance with financial regulations
- D. Storage costs charged by the service provider

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 757

What is the BEST way for an IS auditor to address the risk associated with over-retention of personal data after identifying a large number of customer records retained beyond the retention period defined by law?

- A. Recommend automating deletion of records beyond the retention period.
- B. Schedule regular internal audits to identify records for deletion.
- C. Report the retention period noncompliance to the regulatory authority.
- D. Escalate the over-retention issue to the data privacy officer for follow-up.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 758

Following a breach, what is the BEST source to determine the maximum amount of time before customers must be notified that their personal information may have been compromised?

- A. Industry standards
- B. Information security policy
- C. Incident response plan
- D. Industry regulations

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 759

An IS auditor identifies key controls that have been overridden by management. The NEXT step the IS auditor should take is to:

- A. perform procedures to quantify the irregularities.
- B. report the absence of key controls to regulators.
- C. recommend compensating controls.
- D. withdraw from the engagement.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 760

A security regulation requires the disabling of direct administrator access. Such access must occur through an intermediate server that holds administrator passwords for all systems and records all actions. An IS auditor's PRIMARY concern with this solution would be that:

- A. it is not feasible to implement.
- B. it represents a single point of failure.
- C. segregation of duties is not observed.
- D. access logs may not be maintained.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 761

During an audit of identity and access management, an IS auditor finds that the engagement audit plan does not include the testing of controls that regulate access by third parties. Which of the following would be the auditor's BEST course of action?

- A. Plan to test these controls in another audit.
- B. Escalate the deficiency to audit management.
- C. Add testing of third-party access controls to the scope of the audit.
- D. Determine whether the risk has been identified in the planning documents.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 762

Which of the following is the BEST method for converting a file into a format suitable for data analysis in a forensic investigation?

- A. Extraction
- B. Normalization
- C. Data acquisition
- D. Imaging

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 763

Which of the following is MOST important to include in forensic data collection and preservation procedures?

- A. Maintaining chain of custody
- B. Preserving data integrity
- C. Determining tools to be used
- D. Assuring the physical security of devices

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 764

An organization that has suffered a cyber attack is performing a forensic analysis of the affected users' computers. Which of the following should be of GREATEST concern for the IS auditor reviewing this process?

- A. The chain of custody has not been documented.
- B. The legal department has not been engaged.
- C. An imaging process was used to obtain a copy of the data from each computer.
- D. Audit was only involved during extraction of the information.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 765

Which of the following is the PRIMARY role of an IS auditor with regard to data privacy?

- A. Ensuring compliance with data privacy laws
- B. Communicating data privacy requirements to the organization
- C. Drafting the organization's data privacy policy
- D. Verifying that privacy practices match privacy statements

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 766

Which of the following controls will BEST ensure that the board of directors receives sufficient information about IT?

- A. The CIO reports on performance and corrective actions in a timely manner.
- B. Regular meetings occur between the board, the CIO, and a technology committee.
- C. The CIO regularly sends IT trend reports to the board.
- D. Board members are knowledgeable about IT, and the CIO is consulted on IT issues.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 767

For mission-critical applications with a low recovery time objective (RTO), which of the following is the BEST backup strategy?

- A. Frequent back-ups to tape
- B. Mirroring

- C. Use of virtual tape libraries
- D. Archiving to conventional disk

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 768

The MOST effective way to determine if IT is meeting business requirements is to establish:

- A. industry benchmarks.
- B. organizational goals.
- C. a capability model.
- D. key performance indicators (KPIs).

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 769

Which of the following roles combined with the role of a database administrator (DBA) will create a segregation of duties conflict?

- A. Quality assurance
- B. Systems analyst
- C. Application end user
- D. Security administrator

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 770

When testing segregation of duties, which of the following audit techniques provides the MOST reliable evidence?

- A. Observing daily operations for the area in scope
- B. Evaluating the department structure via the organizational chart
- C. Reviewing departmental procedure handbooks
- D. Interviewing managers and end users

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 771

Which of the following should be reviewed as part of a data integrity test?

- A. Completeness
- B. Confidentiality
- C. Data backup
- D. Redundancy

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 772

Which of the following would BEST provide executive management with current information on IT-related costs and IT performance indicators?

- A. IT dashboard
- B. Risk register
- C. IT service-management plan
- D. Continuous audit reports

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 773

Which of the following will MOST effectively help to manage the challenges associated with end user- developed application systems?

- A. Developing classifications based on risk
- B. Introducing redundant support capacity
- C. Prohibiting creation of executable files
- D. Applying control practices used by IT

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 774

Which of the following is the BEST compensating control for a lack of proper segregation of duties in an IT department?

- A. Authorization forms
- B. Audit trail reviews
- C. System activity logging
- D. Control self-assessment (CSA)

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 775

The BEST way to evaluate a shared control environment is to obtain an assurance report and review which of the following?

- A. Control self-assessment (CSA)
- B. Service level agreement (SLA)
- C. Master service agreement
- D. Complementary user entity controls

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 776

Which of the following is the PRIMARY advantage of the IT portfolio management approach over the balanced scorecard approach when managing IT investments?

- A. The influence of qualitative factors on investment decisions.
- B. Agility in adjusting investment decisions.
- C. Incorporation of organizational strategy in investment decisions.
- D. Use of the organization's risk appetite in investment decisions.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 777

Which of the following is the PRIMARY benefit of including IT management and staff when conducting control self-assessments (CSAs) within an organization?

- A. It helps to identify risk to the business.
- B. It improves the efficiency of business and IT operational processes.
- C. It increases buy-in for more stringent controls.
- D. It reduces the workload of external and internal auditors.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 778

In the IT department where segregation of duties is not feasible due to a limited number of resources, a team member is performing the functions of computer operator and reviewer of application logs. Which of the following would be the IS auditor's BEST recommendation?

- A. Develop procedures to verify that the application logs are not modified.
- B. Prevent the operator from performing application development activities.
- C. Assign an independent second reviewer to verify the application logs.
- D. Restrict the computer operator's access to the production environment.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 779

An IT balanced scorecard is MOST useful in determining the effectiveness of which of the following?

- A. Key IT controls
- B. Change management processes
- C. IT department's financial position
- D. Governance of enterprise IT

Correct Answer: D
Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 780

To help determine whether a controls-reliant approach to auditing financial systems in a company should be used, which sequence of IS audit work is MOST appropriate?

- A. Review of major financial applications followed by a review of IT governance processes
- B. Review of application controls followed by a test of key business process controls
- C. Review of the general IS controls followed by a review of the application controls
- D. Detailed examination of financial transactions followed by review of the general ledger

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 781

A financial services organization has just been granted a banking license. Which of the following is MOST important for the organization to ensure when updating its IT security policy?

- A. The policy has been approved by the board and executive management.
- B. The policy is required to be reviewed at regular intervals.
- C. The policy is consistent with relevant human resources policies.
- D. The policy reflects legislative and regulatory requirements.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 782

An organization has an acceptable use policy in place, but users do not formally acknowledge the policy. Which of the following is the MOST significant risk from this finding?

- A. Violation of industry standards
- B. Lack of user accountability
- C. Noncompliance with documentation requirements
- D. Lack of data for measuring compliance

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 783

When reviewing an organization's security awareness program, it is MOST important to verify that training occurs:

- A. on a continual basis.
- B. within the first few months of employment.
- C. before access to information is granted.
- D. whenever security policies are updated.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 784

During an information security audit of a mid-sized organization, an IS auditor notes that the organization's information security policy is not sufficient. What is the auditor's BEST recommendation for the organization?

- A. Identify and close gaps compared to a best-practice framework.
- B. Perform a benchmark with competitors' policies.
- C. Obtain an external consultant's support to rewrite the policy.
- D. Define roles and responsibilities for regularly updating the policy.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 785

Which of the following is MOST important for an IS auditor to review when evaluating the completeness of an organization's personally identifiable information (PII) inventory?

- A. Data flows
- B. Data retention
- C. Data ownership
- D. Data policy

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 786

Which of the following is the BEST audit procedure to determine whether a firewall is configured in compliance with the organization's security policy?

- A. Reviewing the system log
- B. Reviewing the parameter settings
- C. Interviewing the firewall administrator
- D. Reviewing the actual procedures

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 787

What is the MOST effective way for an IS auditor to determine whether employees understand the organization's information security policy?

- A. Ensure the policy is current.
- B. Survey employees.
- C. Review the organization's employee training log
- D. Ensure the policy is communicated throughout the organization.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 788

Which of the following focus areas is a responsibility of IT management rather than IT governance?

- A. Risk optimization
- B. IT resource optimization
- C. IT controls implementation
- D. Benefits realization

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 789

During an IT governance audit, an IS auditor notes that IT policies and procedures are not regularly reviewed and updated. The GREATEST concern to the IS auditor is that policies and procedures might not:

- A. reflect current practices.
- B. incorporate changes to relevant laws.
- C. be subject to adequate quality assurance (QA).
- D. include new systems and corresponding process changes.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 790

Which of the following falls within the scope of an information security governance committee?

- A. Approving access to critical financial systems
- B. Prioritizing information security technology initiatives
- C. Reviewing content for information security awareness programs
- D. Selecting the organization's external security auditors

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 791

Which of the following BEST indicates that an organization has effective governance in place?

- A. The organization is compliant with local government regulations.
- B. The organization's board of directors executes on the management strategy.
- C. The organization's board of directors reviews metrics for strategic initiatives.
- D. The organization regularly updates governance-related policies and procedures.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 792

Which of the following BEST demonstrates that IT strategy is aligned with organizational goals and objectives?

- A. Organizational strategies are communicated to the chief information officer (CIO).
- B. Business stakeholders are involved in approving the IT strategy.
- C. The chief information officer (CIO) is involved in approving the organizational strategies.
- D. IT strategies are communicated to all business stakeholders.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

<https://www.isaca.org/resources/news-and-trends/industry-news/2020/the-value-of-it-governance>

QUESTION 793

An organization's audit charter PRIMARILY:

- A. describes the auditors' authority to conduct audits.
- B. documents the audit process and reporting standards.
- C. formally records the annual and quarterly audit plans.
- D. defines the auditors' code of conduct.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 794

When deciding whether a third party can be used in resolving a suspected security breach, which of the following should be the MOST important consideration for IT management?

- A. Audit approval
- B. Third-party cost
- C. Incident priority rating
- D. Data sensitivity

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 795

Which of the following would BEST help prioritize various projects in an organization's IT portfolio?

- A. Business cases
- B. Total cost of ownership (TCO)
- C. Industry trends
- D. Enterprise architecture (EA)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 796

When evaluating database management practices, which of the following controls would MOST effectively support data integrity?

- A. System processing output balanced to control totals
- B. System edit checks
- C. User access controls
- D. System-generated duplicate transaction reports

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 797

An IS auditor conducting a follow-up audit learns that previously funded recommendations have not been implemented due to recent budget restrictions. Which of the following should the auditor do NEXT?

- A. Report to the audit committee that the recommendations are still open.
- B. Report the matter to the chief financial officer (CFO) and recommend funding be reinstated.
- C. Close the audit recommendations in the tracking register.
- D. Start an audit of the project funding allocation process.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 798

Which of the following is the PRIMARY benefit of using a capability maturity model?

- A. It provides detailed change management strategies for performance improvement.
- B. It helps the organization develop a roadmap toward its desired level of maturity in each area.
- C. It provides a way to compare against similar organizations' maturity levels.
- D. It helps the organization estimate how long it will take to reach the highest level of maturity in each area.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

<https://www.isaca.org/resources/news-and-trends/isaca-now-blog/2016/building-capability-with-cmmi>

QUESTION 799

What is the MOST critical finding when reviewing an organization's information security management?

- A. No periodic assessments to identify threats and vulnerabilities
- B. No dedicated security officer
- C. No official charter for the information security management system
- D. No employee awareness training and education program

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 800

Of the following, who should approve a release to a critical application that would make the application inaccessible for 24 hours?

- A. Business process owner
- B. Chief information security officer (CISO)
- C. Data custodian
- D. Project manager

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 801

During an exit interview, senior management disagrees with some of the facts presented in the draft audit report and wants them removed from the report. Which of the following would be the auditor's BEST course of action?

- A. Revise the assessment based on senior management's objections
- B. Gather evidence to analyze senior management's objections.
- C. Escalate the issue to audit management.
- D. Finalize the draft audit report without changes.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 802

Which of the following is the MOST important to have in place to build consensus among key stakeholders on the cost-effectiveness of IT?

- A. Standardized enterprise architecture (EA)
- B. A uniform IT chargeback process
- C. IT project governance and management
- D. IT performance monitoring and reporting

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 803

The implementation of an IT governance framework requires that the board of directors of an organization:

- A. approve the IT strategy.
- B. be informed of all IT initiatives.
- C. have an IT strategy committee.
- D. address technical IT issues.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 804

An organization seeks to control costs related to storage media throughout the information life cycle while still meeting business and regulatory requirements. Which of the following is the BEST way to achieve this objective?

- A. Utilize solid state memory.
- B. Implement a data retention policy.
- C. Perform periodic tape backups.
- D. Stream backups to the cloud.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 805

Which of the following is the MOST important consideration for an IS auditor when assessing the adequacy of an organization's information security policy?

- A. Business objectives
- B. Alignment with the IT tactical plan
- C. Compliance with industry best practice
- D. IT steering committee minutes

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 806

An organization implemented a cybersecurity policy last year. Which of the following is the GREATEST indicator that the policy may need to be revised?

- A. A significant increase in external attack attempts
- B. A significant increase in approved exceptions
- C. A significant increase in cybersecurity audit findings
- D. A significant increase in authorized connections to third parties

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 807

When reviewing an organization's information security policies, an IS auditor should verify that the policies have been defined PRIMARILY on the basis of:

- A. industry best practices.
- B. an information security framework.
- C. past information security incidents.
- D. a risk management process.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 808

Which of the following is the BEST use of a maturity model in a small organization?

- A. To develop a roadmap for the organization to achieve the highest maturity level
- B. To identify required actions to close the gap between current and desired maturity levels
- C. To benchmark against peer organizations that have attained the highest maturity level
- D. To assess the current maturity level and the level of compliance with key controls

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 809

Which of the following information security requirements BEST enables the tracking of organizational data in a bring your own device (BYOD) environment?

- A. Employees must sign acknowledgement of the organization's mobile device acceptable use policy.
- B. Employees must use auto-lock features and complex passwords on personal devices.
- C. Employees must immediately report lost or stolen mobile devices containing organizational data.
- D. Employees must enroll their personal devices in the organization's mobile device management program.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 810

End users have been demanding the ability to use their own devices for work, but want to keep personal information out of corporate control. Which of the following would be MOST effective at reducing the risk of security incidents while satisfying user requirements?

- A. Require complex passwords
- B. Implement an acceptable use policy
- C. Enable remote wipe capabilities for the devices
- D. Encrypt corporate data on the devices

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 811

When classifying information, it is MOST important to align the classification to:

- A. industry standards
- B. security policy
- C. business risk
- D. data retention requirements

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 812

Which of the following would be the MOST useful metric for management to consider when reviewing a project portfolio?

- A. Total cost of each project
- B. Expected return divided by total project cost
- C. Net present value (NPV) of the portfolio
- D. Cost of projects divided by total IT cost

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 813

IS management has recently disabled certain referential integrity controls in the database management system (DBMS) software to provide users increased query performance. Which of the following controls will MOST effectively compensate for the lack of referential integrity?

- A. Performance monitoring tools
- B. More frequent data backups
- C. Periodic table link checks
- D. Concurrent access controls

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 814

Which of the following is the PRIMARY benefit of performing a maturity model assessment?

- A. It identifies and fixes attribute weaknesses.
- B. It ensures organizational consistency and improvement.
- C. It facilitates the execution of an improvement plan.
- D. It acts as a measuring tool and progress indicator.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 815

Which of the following is MOST important to review when evaluating the performance of a critical web application?

- A. Business-defined application response times
- B. Feedback from customer satisfaction surveys
- C. Roles and responsibilities for reporting
- D. Strategy for application performance monitoring in the cloud

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 816

When assessing whether an organization's IT performance measures are comparable to other organizations in the same industry, which of the following would be MOST helpful to review?

- A. Utilization reports

- B. Balanced scorecard
- C. Benchmarking surveys
- D. IT governance frameworks

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 817

Which of the following is the BEST indicator of the effectiveness of an organization's portfolio management program?

- A. Percentage of investments achieving their forecasted value
- B. Maturity levels of the value management processes
- C. Experience of the portfolio management personnel
- D. Stakeholder's perception of IT's value

Correct Answer: B

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 818

The PRIMARY objective of IT service level management is to:

- A. improve IT cost control.
- B. increase awareness of IT services.
- C. manage computer operations activities.
- D. satisfy customer requirements.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 819

A core business unit relies on an effective legacy system that does not meet the current security standards and threatens the enterprise network. Which of the following is the BEST course of action to address the situation?

- A. Require that new systems that can meet the standards be implemented.
- B. Document the deficiencies in the risk register.
- C. Develop processes to compensate for the deficiencies.
- D. Disconnect the legacy system from the rest of the network.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 820

Which of the following would BEST enable effective decision-making?

- A. Annualized loss estimates determined from past security events.
- B. A universally applied list of generic threats impacts, and vulnerabilities
- C. Formalized acceptance of risk analysis by business management
- D. A consistent process to analyze new and historical information risk

Correct Answer: D

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 821

A critical server for a hospital has been encrypted by ransomware. The hospital is unable to function effectively without this server. Which of the following would MOST effectively allow the hospital to avoid paying the ransom?

- A. A continual server replication process
- B. A property tested offline backup system
- C. A property configured firewall
- D. Employee training on ransomware

Correct Answer: A

Explanation

Explanation/Reference:

Section: Governance and Management of IT

QUESTION 822

Which of the following security processes will BEST prevent the exploitation of system vulnerabilities?

- A. Patch management
- B. Log monitoring

- C. Antivirus software
- D. Intrusion detection

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 823

Which of the following is MOST likely to be included in computer operating procedures in a large data center?

- A. Instructions for job scheduling
- B. Procedures for resequencing source code
- C. Procedures for utility configuration
- D. Guidance on setting security parameters

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 824

What is the PRIMARY benefit to executive management when audit, risk, and security functions are aligned?

- A. More efficient incident handling
- B. Reduced number of assurance reports
- C. More effective decision making
- D. More timely risk reporting

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 825

Reevaluation of risk is MOST critical when there is:

- A. resistance to the implementation of mitigating controls
- B. a change in security policy
- C. a management request for updated security reports
- D. a change in the threat landscape

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 826

Which of the following is the MOST important role of the information security manager when the organization is in the process of adopting emerging technologies?

- A. Understanding the impact on existing resources
- B. Assessing how peer organizations using the same technologies have been impacted
- C. Developing training for end users to familiarize them with the new technology
- D. Reviewing vendor documentation and service levels agreements

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 827

Which of the following BEST enables staff acceptance of information security policies?

- A. Strong senior management support
- B. Adequate security funding
- C. Computer-based training
- D. A robust incident response program

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 828

Which of the following is the MOST important element when developing an information security strategy?

- A. Identifying applicable laws and regulations
- B. Identifying information assets
- C. Determining the risk management methodology
- D. Aligning security activities with organizational goals

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 829

An organization has outsourced many application development activities to a third party that uses contract programmers extensively. Which of the following would provide the BEST assurance that the third party's contract programmers comply with the organization's security policies?

- A. Perform periodic security assessments of the contractors' activities.
- B. Conduct periodic vulnerability scans of the application.
- C. Include penalties for noncompliance in the contracting agreement.
- D. Require annual signed agreements of adherence to security policies.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 830

When choosing the best controls to mitigate risk to acceptable levels, the information security manager's decision should be MAINLY driven by:

- A. cost-benefit analysis
- B. regulatory requirements
- C. best practices
- D. control framework

Correct Answer: B
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 831

What is the FIRST line of defense against criminal insider activities?

- A. Validating the integrity of personnel
- B. Monitoring employee activities
- C. Signing security agreements by critical personnel
- D. Stringent and enforced access controls

Correct Answer: D
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 832

An information security manager is assisting in the development of the request for proposal (RFP) for a new outsourced service. This will require the third party to have access to critical business information. The security manager should focus PRIMARILY on defining:

- A. security requirements for the process being outsourced
- B. security metrics
- C. service level agreements (SLAs)
- D. risk-reporting methodologies

Correct Answer: C
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 833

The MOST useful technique for maintaining management support for the information security program is:

- A. identifying the risks and consequences of failure to comply with standards
- B. benchmarking the security programs of comparable organizations
- C. implementing a comprehensive security awareness and training program
- D. informing management about the security of business operations

Correct Answer: A
Explanation

Explanation/Reference:
Section: Governance and Management of IT

QUESTION 834

An organization developed a comprehensive three-year IT strategic plan. Halfway into the plan, a major legislative change impacting the organization is enacted. Which of the following should be management's NEXT course of action?

- A. Develop specific procedural documentation related to the changed legislation.
- B. Assess the legislation to determine whether changes are required to the strategic IT plan.
- C. Perform a risk assessment of the legislative changes.
- D. Develop a new IT strategic plan that encompasses the new legislation.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 835

Which of the following is the MOST important factor when an organization is developing information security policies and procedures?

- A. Cross-references between policies and procedures
- B. Inclusion of mission and objectives
- C. Compliance with relevant regulations
- D. Consultation with management

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 836

Which of the following is the MOST important advantage of participating in beta testing of software products?

- A. It improves vendor support and training.
- B. It enables an organization to gain familiarity with new products and their functionality.
- C. It increases an organization's ability to retain staff who prefer to work with new technology.
- D. It enhances security and confidentiality.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 837

The maturity level of an organization's problem management support function is optimized when the function:

- A. proactively provides solutions
- B. has formally documented the escalation process
- C. analyzes critical incidents to identify root cause
- D. resolves requests in a timely manner

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 838

To preserve chain of custody following an internal server compromise, which of the following should be the FIRST step?

- A. Take a system image including memory dump
- B. Safely shut down the server
- C. Replicate the attack using the remaining evidence
- D. Trace the attacking route

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Governance and Management of IT

QUESTION 839

When planning for the implementation of a new system, an organization will opt for a parallel run PRIMARILY to:

- A. ensure that the system meets required user response time.
- B. validate system processing.
- C. facilitate the training of new personnel.
- D. verify that system interfaces were implemented.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 840

In a typical network architecture used for e-commerce, a load balancer is normally found between the:

- A. routers and the web servers.
- B. mail servers and the mail repositories.
- C. users and the external gateways.
- D. databases and the external gateways.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 841

An organization is choosing key performance indicators (KPIs) for its information security management. Which of the following KPIs would provide stakeholders with the MOST useful information about whether information security risk is being managed?

- A. Time from initial reporting of an incident to appropriate escalation
- B. Time from identifying a security threat to implementing a solution
- C. The number of security controls implemented
- D. The number of security incidents during the past quarter

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 842

Which of the following is a detective control that can be used to uncover unauthorized access to information systems?

- A. Requiring long and complex passwords for system access
- B. Implementing a security information and event management (SIEM) system
- C. Requiring internal audit to perform periodic reviews of system access logs
- D. Protecting access to the data center with multifactor authentication

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 843

Which of the following control checks would utilize data analytics?

- A. Evaluating configuration settings for the credit card application system
- B. Reviewing credit card applications submitted in the past month for blank data fields
- C. Attempting to submit credit card applications with blank data fields
- D. Reviewing the business requirements document for the credit card application system

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 844

Which of the following is the BEST way to control scope creep during application system development?

- A. Involve key stakeholders.
- B. Implement project steering committee review.
- C. Implement a quality management system.
- D. Establish key performance indicators (KPIs).

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 845

An organization is using a single account shared by personnel for its social networking marketing page. Which of the following is the BEST method to maintain accountability over the account?

- A. Reviewing access rights on a periodic basis
- B. Integrating the account with a single sign-on
- C. Regular monitoring of proxy server logs
- D. Implementing an account password check-out process

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 846

An organization has implemented an enhanced password policy for business applications which requires significantly more business unit resources to support clients. The BEST approach to obtain the support of business unit management would be to:

- A. elaborate on the positive impact to information security.
- B. present industry benchmarking results to business units.
- C. discuss the risk and impact of security incidents if not implemented.
- D. present an analysis of the cost and benefit of the changes.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 847

When using a newly implemented security information and event management (SIEM) infrastructure, which of the following should be considered FIRST?

- A. Report distribution
- B. Encryption
- C. Tuning
- D. Retention

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 848

An organization has an approved bring your own device (BYOD) program. Which of the following is the MOST effective method to enforce application control on personal devices?

- A. Implement a mobile device management solution.
- B. Establish a mobile device acceptable use policy.
- C. Implement a web application firewall.
- D. Educate users regarding the use of approved applications.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 849

An organization's HR department would like to outsource its employee management system to a cloud-hosted solution due to features and cost savings offered. Management has identified this solution as a business need and wants to move forward. What should be the PRIMARY role of information security in this effort?

- A. Ensure a security audit is performed of the service provider.
- B. Ensure the service provider has the appropriate certifications.
- C. Determine how to securely implement the solution.
- D. Explain security issues associated with the solution to management.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 850

During which phase of an incident response process should corrective actions to the response procedure be considered and implemented?

- A. Eradication
- B. Identification
- C. Review
- D. Containment

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 851

An emergency change was made to an IT system as a result of a failure. Which of the following should be of GREATEST concern to the organization's information security manager?

- A. The operations team implemented the change without regression testing.
- B. The change did not include a proper assessment of risk.
- C. Documentation of the change was made after implementation.
- D. The information security manager did not review the change prior to implementation.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 852

Which of the following is MOST critical to the successful implementation of information security within an organization?

- A. Strong risk management skills exist within the information security group.
- B. Budget is allocated for information security tools.
- C. The information security manager is responsible for setting information security policy.
- D. Security is effectively marketed to all managers and employees.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 853

Which of the following would contribute MOST to employees' understanding of data handling responsibilities?

- A. Requiring staff acknowledgement of security policies
- B. Labeling documents according to appropriate security classification
- C. Implementing a tailored security awareness training program
- D. Demonstrating support by senior management of the security program

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 854

An organization implemented a mandatory information security awareness training program a year ago. What is the BEST way to determine its effectiveness?

- A. Analyze responses from an employee survey on training satisfaction.
- B. Analyze results from training completion reports.
- C. Analyze results of a social engineering test.
- D. Analyze findings from previous audit reports.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 855

Planning for the implementation of an information security program is MOST effective when it:

- A. uses risk-based analysis for security projects.
- B. applies technology-driven solutions to identified needs.
- C. uses decision trees to prioritize security projects.
- D. applies gap analysis to current and future business plans.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 856

The MOST important factors in determining the scope and timing for testing a business continuity plan are:

- A. manual processing capabilities and the test location.
- B. the importance of the function to be tested and the cost of testing.
- C. the experience level of personnel and the function location.
- D. prior testing results and the degree of detail of the business continuity plan.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 857

Which of the following will identify a deviation in the information security management process from generally accepted standards of good practices?

- A. Gap analysis
- B. Risk assessment
- C. Business impact analysis (BIA)
- D. Penetration testing

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 858

Which of the following is MOST important for an organization to complete prior to developing its disaster recovery plan (DRP)?

- A. Support staff skill gap analysis
- B. Comprehensive IT inventory
- C. Business impact analysis (BIA)
- D. Risk assessment

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 859

An application development team is also promoting changes to production for a critical financial application. Which of the following would be the BEST control to reduce the associated risk?

- A. Implementing a change management code review
- B. Implementing a peer review process
- C. Performing periodic audits
- D. Submitting change logs to the business manager for review

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 860

A start-up organization wants to develop a data loss prevention program (DLP). The FIRST step should be to implement:

- A. data encryption.
- B. access controls.
- C. data classification.
- D. security awareness training.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 861

An organization is in the process of rolling out a new inventory software tool to replace a suite of verified individual spreadsheet-based inventory solutions. Which of the following is MOST important to help ensure ongoing data integrity within the new inventory tool?

- A. Restricting edit access for the new tool to data owners only
- B. Ensuring data quality at the point of data entry
- C. Requiring key inventory data points to be mandatory fields in the new tool
- D. Conducting a post-migration quality assurance review

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 862

Which of the following is MOST critical to include when developing a data loss prevention (DLP) policy?

- A. Identification of the relevant network channels requiring protection
- B. Identification of the users, groups and roles to whom the policy will apply
- C. Identification of enforcement actions
- D. Identification of the content to protect

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 863

Which of the following is the BEST methodology to use for estimating the complexity of developing a large business application?

- A. Function point analysis
- B. Software cost estimation
- C. Work breakdown structure
- D. Critical path analysis

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 864

Which of the following access rights presents the GREATEST risk when granted to a new member of the system development staff?

- A. Execute access to development program libraries
- B. Write access to development data libraries
- C. Execute access to production program libraries
- D. Write access to production program libraries

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 865

Which is the PRIMARY objective of evaluating the readiness of information systems for implementation?

- A. Determine whether IT systems projects are on schedule.
- B. Determine whether the systems comply with the organization's policy.

- C. Determine whether the systems meet user requirements.
- D. Determine whether the systems meet business requirements.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 866

An organization is considering allowing users to connect personal devices to the corporate network. Which of the following should be done FIRST?

- A. Configure users on the mobile device management solution.
- B. Create inventory records of personal devices.
- C. Implement an acceptable use policy.
- D. Conduct security awareness training.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 867

Which of the following is MOST important for the successful establishment of a security vulnerability management program?

- A. A comprehensive asset inventory
- B. A tested incident response plan
- C. An approved patching policy
- D. A robust tabletop exercise plan

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 868

An organization's audit charter should:

- A. set the enterprise strategic direction.
- B. detail the audit objectives.
- C. define the auditors' right to access information.
- D. include the IS audit plan.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 869

Which of the following is the MOST important privacy consideration for an organization that uses a cloud service provider to process customer data?

- A. Data privacy must be monitored in accordance with industry standards and best practices.
- B. All customer data transferred to the service provider must be reported to the regulatory authority.
- C. No personal information may be transferred to the service provider without the consent of the customer.
- D. Data privacy must be managed in accordance with the regulations applicable to the organization.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 870

Which of the following is critical to the successful establishment of an enterprise IT architecture?

- A. A well-defined data migration policy
- B. Comparison of the architecture with that of other organizations
- C. An architecture encompassing only critical systems
- D. Organizational support for standardization

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 871

Which of the following is MOST important in determining a project's feasibility?

- A. The organization's main competitor has initiated a similar project.
- B. The IT steering committee endorses the project.
- C. A project management methodology is established.
- D. The project's value is established in an approved business case.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 872
The MAIN consideration when designing an incident escalation plan should be ensuring that:

- A. information assets are classified.
- B. appropriate stakeholders are involved.
- C. high-impact risks have been identified.
- D. requirements cover forensic analysis.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 873
Which of the following should be an information security manager's MOST important consideration when conducting a physical security review of a potential outsourced data center?

- A. Environmental factors of the surrounding location
- B. Proximity to law enforcement
- C. Availability of network circuit connections
- D. Distance of the data center from the corporate office

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 874
What should be the information security manager's MOST important consideration when planning a disaster recovery test?

- A. Stakeholder notification procedures
- B. Organization-wide involvement
- C. Impact to production systems
- D. Documented escalation processes

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 875
The use of a business case to obtain funding for an information security investment is MOST effective when the business case:

- A. translates information security policies and standards into business requirements.
- B. articulates management's intent and information security directives in clear language.
- C. relates the investment to the organization's strategic plan.
- D. realigns information security objectives to organizational strategy.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 876
An organization is deciding whether to outsource its customer relationship management systems to a provider located in another country. Which of the following should be the PRIMARY influence in the outsourcing decision?

- A. Time zone differences
- B. The service provider's disaster recovery plan
- C. Cross-border privacy laws
- D. Current geopolitical conditions

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 877
An organization is MOST at risk from a new worm being introduced through the intranet when:

- A. executable code is run from inside the firewall
- B. system software does not undergo integrity checks
- C. hosts have static IP addresses
- D. desktop virus definition files are not up to date

Correct Answer: D
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 878

Which of the following is MOST important for an information security manager to ensure is included in a business case for a new system?

- A. Intangible benefits of the system
- B. Risk associated with the system
- C. Effectiveness of controls
- D. Audit-logging capabilities

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 879

During a post-incident review, the sequence and correlation of actions must be analyzed PRIMARLY based on:

- A. interviews with personnel
- B. a consolidated event time line
- C. logs from systems involved
- D. documents created during the incident

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 880

Which of the following BEST enables effective closure of noncompliance issues?

- A. Insuring against the risk
- B. Performing control self-assessments
- C. Capturing issues in a risk register
- D. Executing an approved mitigation plan

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 881

The BEST way to obtain funding from senior management for a security awareness program is to:

- A. meet regulatory requirements
- B. produce an impact analysis report of potential breaches
- C. demonstrate that the program will adequately reduce risk
- D. produce a report of organizational risks

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 882

In a cloud technology environment, which of the following would pose the GREATEST challenge to the investigation of security incidents?

- A. Data encryption
- B. Access to the hardware
- C. Compressed customer data
- D. Non-standard event logs

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 883

A finance department director has decided to outsource the organization's budget application and has identified potential providers. Which of the following actions should be initiated FIRST by the information security manager?

- A. Validate that connectivity to the service provider can be made securely.
- B. Obtain audit reports on the service providers hosting environment.
- C. Review the disaster recovery plans (DRP) of the providers.
- D. Align the roles of the organization's and the service providers' staffs.

Correct Answer: B

Explanation**Explanation/Reference:**

QUESTION 884

When considering whether to adopt bring your own device (BYOD), it is MOST important for the information security manager to ensure that:

- A. security controls are applied to each device when joining the network
- B. business leaders have an understanding of security risks
- C. users have read and signed acceptable use agreements
- D. the applications are tested prior to implementation

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 885

Hamid needs to shift users from using the application from the existing (Old) system to the replacing (new) system. His manager Lily has suggested he uses an approach in which the newer system is changed over from the older system on a cutoff date and time and the older system is discontinued once the changeover to the new system takes place. Which of the following changeover approach is suggested by Lily?

- A. Parallel changeover
- B. Phased changeover
- C. Abrupt changeover
- D. Pilot changeover

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation In the abrupt changeover approach the newer system is changed over from the older system on a cutoff date and time, and the older system is discontinued once changeover to the new system takes place. Changeover refers to an approach to shift users from using the application from the existing (old) system to the replacing (new) system.

Changeover to newer system involves four major steps or activities Conversion of files and programs; test running on test bed

Installation of new hardware, operating system, application system and the migrated data.

Training employees or user in groups

Scheduling operations and test running for go-live or changeover

Some of the risk areas related to changeover includes:

Asset safeguarding

Data integrity

System effectiveness

Change management challenges

Duplicate or missing records

The following were incorrect answers:

Parallel changeover This technique includes running the old system, then running both the old and new systems in parallel and finally full changing over to the new system after gaining confidence in the working of new system.

Phased Changeover -In this approach the older system is broken into deliverables modules. Initially, the first module of older system is phased out using the first module of a new system. Then, the second module of the newer system is phased out, using the second module of the newer system and so forth until reaching the last module.

Pilot changeover Not a valid changeover type.

CISA review manual 2014 Page number 172

QUESTION 886

An IT management group has developed a standardized security control checklist and distributed it to the control self-assessors in each organizational unit. Which of the following is the GREATEST risk in this approach?

- A. Delayed feedback may increase exposures
- B. Over time the checklist may become outdated
- C. Assessors may manipulate the results
- D. Business-specific vulnerabilities may be overlooked

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 887

Which of the following would create the GREATEST risk when migrating a critical legacy system to a new system?

- A. Using agile development methodology
- B. Following a phased approach
- C. Following a direct cut-over approach
- D. Maintaining parallel systems

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 888

The GREATEST benefit of using a prototyping approach in software development is that it helps to:

- A. decrease the time allocated for user testing and review
- B. minimize scope changes to the system
- C. conceptualize and clarify requirements
- D. improve efficiency of quality assurance (QA) testing

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 889

A company is using a software developer for a project. At which of the following points should the software quality assurance (QA) plan be developed?

- A. As part of software definition
- B. During the feasibility phase
- C. Prior to acceptance testing
- D. As part of the design phase

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 890

During development of an information security policy, which of the following would BEST ensure alignment to business objectives?

- A. Incorporation of industry best practices
- B. Linkage between policy and procedures
- C. Use of a balanced scorecard
- D. Input from relevant stakeholders

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 891

To develop meaningful recommendations for findings, which of the following is MOST important for an IS auditor to determine and understand?

- A. Criteria
- B. Responsible party
- C. Impact
- D. Root cause

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 892

Which of the following MUST be included in emergency change control procedures?

- A. Obtaining user management approval before implementing the changes
- B. Updating production source libraries to reflect the changes
- C. Using an emergency ID to move production programs into development
- D. Requesting that the help desk makes the changes

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 893

Which of the following would BEST demonstrate that an effective disaster recovery plan (DRP) is in place?

- A. Periodic risk assessment
- B. Full operational test
- C. Frequent testing of backups
- D. Annual walk-through testing

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 894

The PRIMARY reason for allocating sufficient time between the "go-live" phase of a new system and conducting a post-implementation review is to:

- A. update project requirements and design documentation
- B. increase availability of system implementation team resources

- C. allow the system to stabilize in production
- D. obtain sign-off on the scope of post-implementation review

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 895

A maturity model is useful in the assessment of IT service management because it:

- A. provides a benchmark for process improvement
- B. defines the level of control required to meet business needs
- C. indicates the service levels required for the business area
- D. specifies the mechanism needed to achieve defined service levels

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 896

Which of the following should be the FIRST step when drafting an incident response plan for a new cyber- attack scenario?

- A. Schedule response testing
- B. Create a new incident response team
- C. Create a reporting template
- D. Identify relevant stakeholders

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 897

Which of the following practices associated with capacity planning provides the GREATEST assurance that future incidents related to server performance will be prevented?

- A. Anticipating current service level agreements (SLAs) will remain unchanged
- B. Prorating the current processing workloads
- C. Negotiating agreements to acquire required cloud services
- D. Duplicating existing disk drive systems to improve redundancy and data storage

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 898

In a typical (system development life cycle) SDLC, which group is PRIMARILY responsible for confirming compliance with requirements?

- A. Steering committee
- B. Risk management
- C. Quality assurance (QA)
- D. Internal audit

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 899

A company is planning to implement a new administrative system at many sites. The new system contains four integrated modules. Which of the following implementation approaches would be MOST appropriate?

- A. Parallel implementation module by module
- B. Pilot run of the new system
- C. Full implementation of the new system
- D. Parallel run at all locations

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 900

A change to the scope of an IT project has been formally submitted to the project manager. What should the project manager do NEXT?

- A. Update the project plan to reflect the change in scope
- B. Discuss the change with the project team and determine if it should be approved

- C. Escalate the change to the change advisory board for approval
- D. Determine how the change will affect the schedule and budget

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 1

Which of the following should be the MOST important consideration when prioritizing the funding for competing IT projects?

- A. Criteria used to determine the benefits of projects
- B. Skills and capabilities within the project management team
- C. Quality and accuracy of the IT project inventory
- D. Senior management preferences

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 2

Which of the following activities should occur after a business impact analysis (BIA)?

- A. Identify threats to the IT environment
- B. Identify critical applications
- C. Analyze recovery options
- D. Review the computing and user environment

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 3

The MOST important function of a business continuity plan is to:

- A. ensure that the critical business functions can be recovered
- B. provide procedures for evaluating tests of the business continuity plan
- C. provide a schedule of events that has to occur if there is a disaster
- D. ensure that all business functions are restored

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 4

Which of the following is MOST useful for determining whether the goals of IT are aligned with the organization's goals?

- A. Balanced scorecard
- B. Enterprise architecture (EA)
- C. Key performance indicators (KPIs)
- D. Enterprise dashboard

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 5

During an internal audit review of an HR recruitment system implementation, the IS auditor notes a number of

defects were unresolved at the time the system went live. Which of the following is the auditor's MOST important task prior to formulating an audit opinion?

- A. Identify the root cause of the defects to confirm severity.
- B. Review the user acceptance test results.
- C. Verify risk acceptance by the project steering committee.
- D. Confirm the timeline for migration of the defects.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 6

A company has implemented an IT segregation of duties policy. In a role-based environment, which of the following roles may be assigned to an approach developer?

- A. IT operator
- B. Database administration
- C. System administration
- D. Emergency support

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 7

The BEST way to evaluate the effectiveness of a newly developed application is to:

- A. perform a post-implementation review.
- B. analyze load-testing results.
- C. review acceptance-testing results.
- D. perform a pre-implementation review.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 8

What is the BEST indicator of successful implementation of an organization's information security policy?

- A. Reduced number of successful phishing incidents
- B. Reduced number of help desk calls
- C. Reduced number of noncompliance penalties incurred
- D. Reduced number of false-positive security events

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 9

An organization is in the process of deciding whether to allow a bring your own device (BYOD) program. If approved, which of the following should be the FIRST control required before implementation?

- A. Device baseline configurations
- B. Device registration
- C. An acceptable use policy
- D. An awareness program

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 10

A (chief information officer) CIO has asked an IS auditor to implement several security controls for an organization's IT processes and systems. The auditor should:

- A. perform the assignment and future audits with due professional care.
- B. obtain approval from executive management for the implementation.
- C. refuse due to independence issues.
- D. communicate the conflict of interest to audit management.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 11

An IS auditor reviewing the acquisition of new equipment would consider which of the following to be a significant weakness?

- A. Staff involved in the evaluation were aware of the vendors being evaluated.
- B. Independent consultants prepared the request for proposal (RFP) documents.
- C. Evaluation criteria were finalized after the initial assessment of responses.
- D. The closing date for responses was extended after a request from potential vendors.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 12

A start-up company acquiring servers for its order-taking system is unable to predict the volume of transactions. Which of the following is MOST important for the company to consider?

- A. Scalability
- B. Configuration
- C. Optimization
- D. Compatibility

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 13

A security company and service provider have merged, and the CEO has requested one comprehensive set of security policies be developed for the newly formed company. The IS auditor's BEST recommendation would be to:

- A. conduct a policy gap assessment.
- B. adopt an industry standard security policy.
- C. implement the service provider's policies.
- D. implement the security company's policies.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 14

An audit committee is reviewing an annual IT risk assessment. Which of the following is the BEST justification for the audits selected?

- A. Likelihood of an IT process failure
- B. Key IT general process controls
- C. Applications impacted
- D. Underlying business risks

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 15

When developing a risk-based IS audit plan, the PRIMARY focus should be on functions:

- A. considered important by IT management.
- B. with the most ineffective controls.
- C. with the greatest number of threats.
- D. considered critical to business operations.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 16

Which of the following is the GREATEST risk associated with in-house program development and customization?

- A. The lack of a test environment
- B. The lack of a quality assurance function
- C. The lack of secure coding expertise
- D. The lack of documentation for programs developed.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 17

Which of the following access control situations represents the MOST serious control weakness?

- A. Computer operators have access to system level flowcharts.
- B. Programmers have access to development hardware.
- C. End users have access to program development tools.
- D. System developers have access to production data.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 18

Which of the following could an IS auditor recommend to improve the estimated resources required in system development?

- A. Business areas involvement
- B. Prototyping
- C. Function point analysis
- D. CASE tools

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 19

Which of the following would be a result of utilizing a top-down maturity model process?

- A. A means of benchmarking the effectiveness of similar processes with peers
- B. Identification of older, more established processes to ensure timely review
- C. Identification of processes with the most improvement opportunities
- D. A means of comparing the effectiveness of other processes within the enterprise

Correct Answer: C
Explanation

Explanation/Reference:
 Section: Information System Acquisition, Development and Implementation

QUESTION 20
 Which of the following is the BEST source of information when assessing the amount of time a project will take?

- A. GANTT chart
- B. Workforce estimate
- C. Critical path analysis
- D. Scheduling budget

Correct Answer: A
Explanation

Explanation/Reference:
 Section: Information System Acquisition, Development and Implementation

QUESTION 21
 Which of the following is MOST important for an effective control self-assessment program?

- A. Determining the scope of the assessment
- B. Evaluating changes to the risk environment
- C. Understanding the business process
- D. Performing detailed test procedures

Correct Answer: C
Explanation

Explanation/Reference:
 Section: Information System Acquisition, Development and Implementation

QUESTION 22
 A new information security manager is charged with reviewing and revising the information security strategy. The information security manager's FIRST course of action should be to gain an understanding of the organization's:

- A. security architecture
- B. risk register
- C. internal control framework
- D. business strategy

Correct Answer: D
Explanation

Explanation/Reference:
 Section: Information System Acquisition, Development and Implementation

QUESTION 23
 Which device acting as a translator is used to connect two networks or applications from layer 4 up to layer 7 of the ISO/OSI Model?

- A. Bridge
- B. Repeater
- C. Router
- D. Gateway

Correct Answer: D
Explanation

Explanation/Reference:
 Section: Information System Acquisition, Development and Implementation A gateway is used to connect two networks using dissimilar protocols at the lower layers or it could also be at the highest level of the protocol stack.

Important Note:

For the purpose of the exam, you have to remember that a gateway is not synonymous to the term firewall.

The second thing you must remember is the fact that a gateway acts as a translation device. It could be used to translate from IPX to TCP/IP for example. It could be used to convert different types of applications protocols and allow them to communicate together. A gateway could be at any of the OSI layers but usually tends to be higher up in the stack.

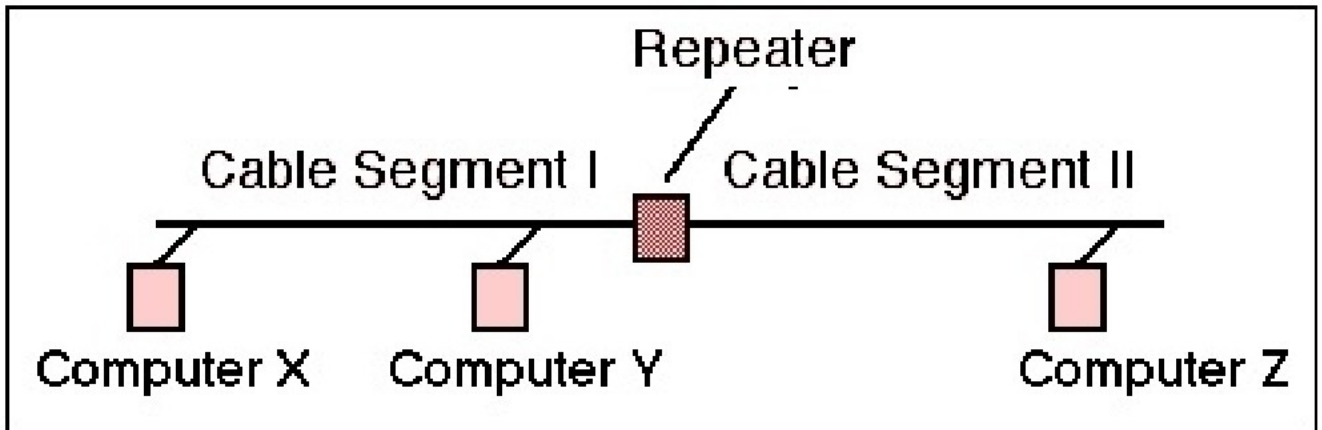
For your exam you should know the information below:

Repeaters

A repeater provides the simplest type of connectivity, because it only repeats electrical signals between cable segments, which enables it to extend a network. Repeaters work at the physical layer and are add-on devices for extending a network connection over a greater distance. The device amplifies signals because signals attenuate the farther they have to travel.

Repeaters can also work as line conditioners by actually cleaning up the signals. This works much better when amplifying digital signals than when amplifying analog signals, because digital signals are discrete units, which makes extraction of background noise from them much easier for the amplifier. If the device is amplifying analog signals, any accompanying noise often is amplified as well, which may further distort the signal. A hub is a multi-port repeater. A hub is often referred to as a concentrator because it is the physical communication device that allows several computers and devices to communicate with each other. A hub does not understand or work with IP or MAC addresses. When one system sends a signal to go to another system connected to it, the signal is broadcast to all the ports, and thus to all the systems connected to the concentrator.

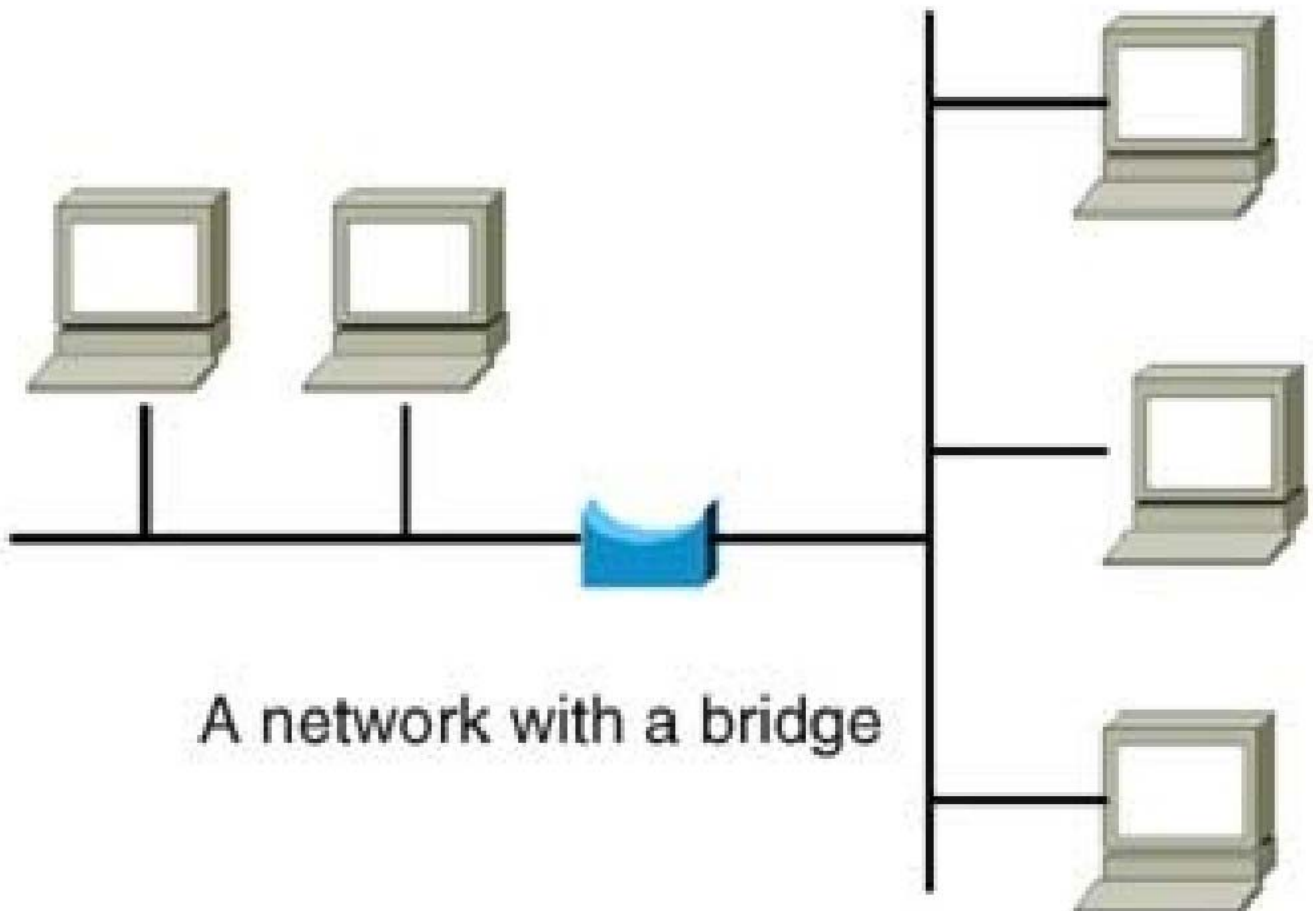
Repeater



Bridges

A bridge is a LAN device used to connect LAN segments. It works at the data link layer and therefore works with MAC addresses. A repeater does not work with addresses; it just forwards all signals it receives. When a frame arrives at a bridge, the bridge determines whether or not the MAC address is on the local network segment. If the MAC address is not on the local network segment, the bridge forwards the frame to the necessary network segment.

Bridge



Routers

Routers are layer 3, or network layer, devices that are used to connect similar or different networks. (For example, they can connect two Ethernet LANs or an Ethernet LAN to a Token Ring LAN.) A router is a device that has two or more interfaces and a routing table so it knows how to get packets to their destinations. It can filter traffic based on access control lists (ACLs), and it fragments packets when necessary. Because routers have more network-level knowledge, they can perform higher-level functions, such as calculating the shortest and most economical path between the sending and receiving hosts.

Router and Switch

Router



8-port Switch



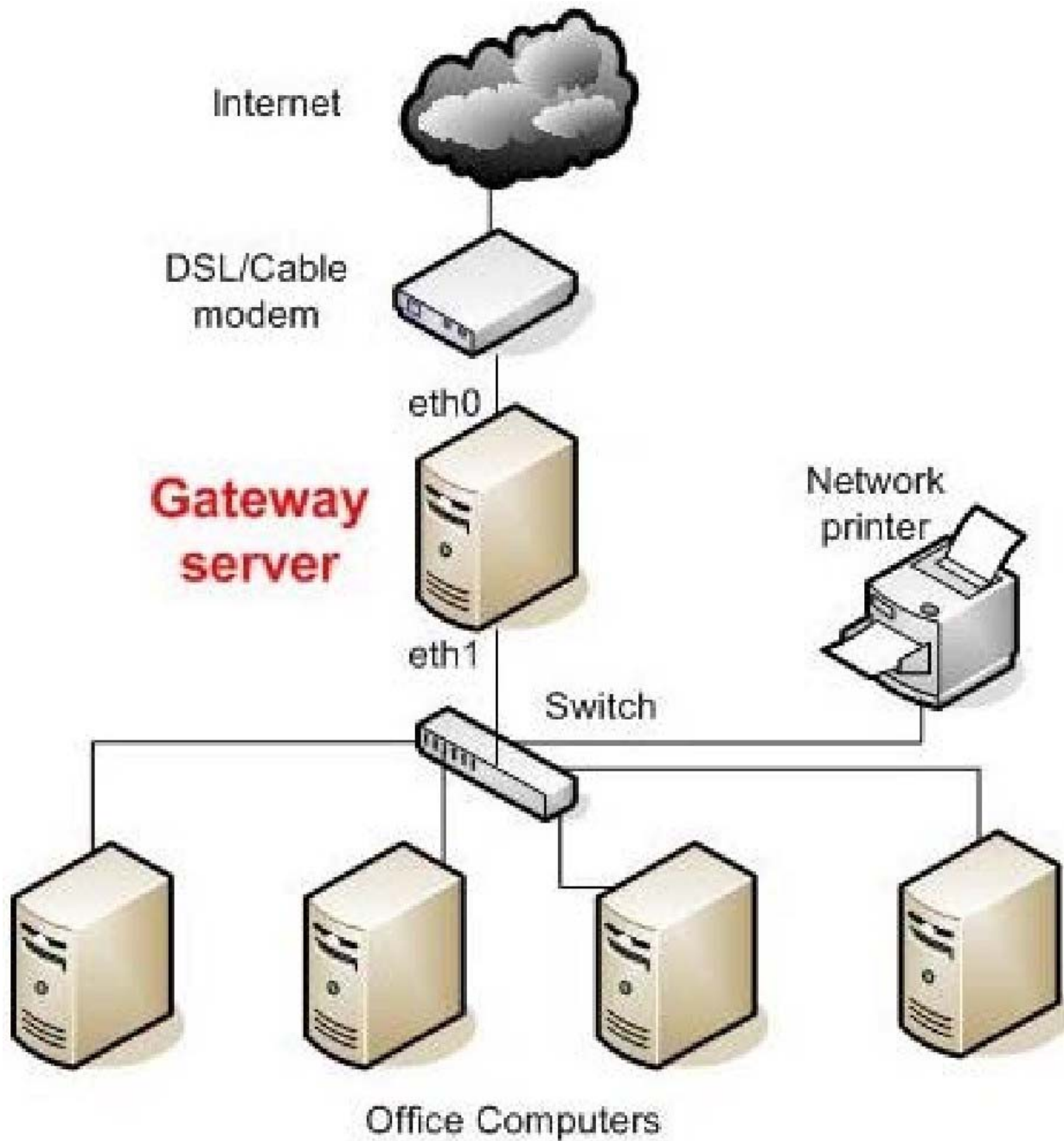
Switches

Switches combine the functionality of a repeater and the functionality of a bridge. A switch amplifies the electrical signal, like a repeater, and has the built-in circuitry and intelligence of a bridge. It is a multi-port connection device that provides connections for individual computers or other hubs and switches.

Gateways

Gateway is a general term for software running on a device that connects two different environments and that many times acts as a translator for them or somehow restricts their interactions. Usually a gateway is needed when one environment speaks a different language, meaning it uses a certain protocol that the other environment does not understand. The gateway can translate Internetwork Packet Exchange (IPX) protocol packets to IP packets, accept mail from one type of mail server and format it so another type of mail server can accept and understand it, or connect and translate different data link technologies such as FDDI to Ethernet.

Gateway Server



The following answers are incorrect:

Repeater - A repeater provides the simplest type of connectivity, because it only repeats electrical signals between cable segments, which enables it to extend a network. Repeaters work at the physical layer and are add-on devices for extending a network connection over a greater distance. The device amplifies signals because signals attenuate the farther they have to travel.

Bridges - A bridge is a LAN device used to connect LAN segments. It works at the data link layer and therefore works with MAC addresses. A repeater does not work with addresses; it just forwards all signals it receives.

When a frame arrives at a bridge, the bridge determines whether or not the MAC address is on the local network segment. If the MAC address is not on the local network segment, the bridge forwards the frame to the necessary network segment.

Routers - Routers are layer 3, or network layer, devices that are used to connect similar or different networks. (For example, they can connect two Ethernet LANs or an Ethernet LAN to a Token Ring LAN.) A router is a device that has two or more interfaces and a routing table so it knows how to get packets to their destinations. It can filter traffic based on access control lists (ACLs), and it fragments packets when necessary.

CISA review manual 2014 Page number 263

Official ISC2 guide to CISSP CBK 3rd Edition Page number 229 and 230

QUESTION 24

Which of the following is a telecommunication device that translates data from digital to analog form and back to digital?

- A. Multiplexer
- B. Modem
- C. Protocol converter
- D. Concentrator

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation A modem is a device that translates data from digital form and then back to digital for communication over analog lines.

Reference: Information Systems Audit and Control Association,

Certified Information Systems Auditor 2002 review manual, Chapter 3: Technical Infrastructure and Operational Practices (page 114).

QUESTION 25

Which of the following transmission media would NOT be affected by cross talk or interference?

- A. Copper cable
- B. Radio System
- C. Satellite radio link
- D. Fiber optic cables

Correct Answer: D
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Only fiber optic cables are not affected by crosstalk or interference.

For your exam you should know the information about transmission media:

Copper Cable

Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data.

Copper has been used in electric wiring since the invention of the electromagnet and the telegraph in the 1820s. The invention of the telephone in 1876 created further demand for copper wire as an electrical

conductor.

Copper is the electrical conductor in many categories of electrical wiring. Copper wire is used in power generation, power transmission, power distribution, telecommunications, electronics circuitry, and countless types of electrical equipment. Copper and its alloys are also used to make electrical contacts. Electrical wiring in buildings is the most important market for the copper industry. Roughly half of all copper mined is used to manufacture electrical wire and cable conductors.

Copper Cable



Coaxial cable

Coaxial cable, or coax (pronounced 'ko.aks), is a type of cable that has an inner conductor surrounded by a tubular insulating layer, surrounded by a tubular conducting shield. Many coaxial cables also have an insulating outer sheath or jacket. The term coaxial comes from the inner conductor and the outer shield sharing a geometric axis. Coaxial cable was invented by English engineer and mathematician Oliver Heaviside, who patented the design in 1880. Coaxial cable differs from other shielded cable used for carrying lower-frequency signals, such as audio signals, in that the dimensions of the cable are controlled to give a precise, constant conductor spacing, which is needed for it to function efficiently as a radio frequency transmission line.

Coaxial cable is expensive and does not support many LAN's. It supports data and video Coaxial Cable



Fiber optics

An optical fiber cable is a cable containing one or more optical fibers that are used to carry light. The optical fiber elements are typically individually coated with plastic layers and contained in a protective tube suitable for the environment where the cable will be deployed. Different types of cable are used for different applications, for example long distance telecommunication, or providing a high-speed data connection between different parts of a building.

Fiber optics used for long distance, hard to splice, not vulnerable to cross talk and difficult to tap. It supports voice data, image and video.

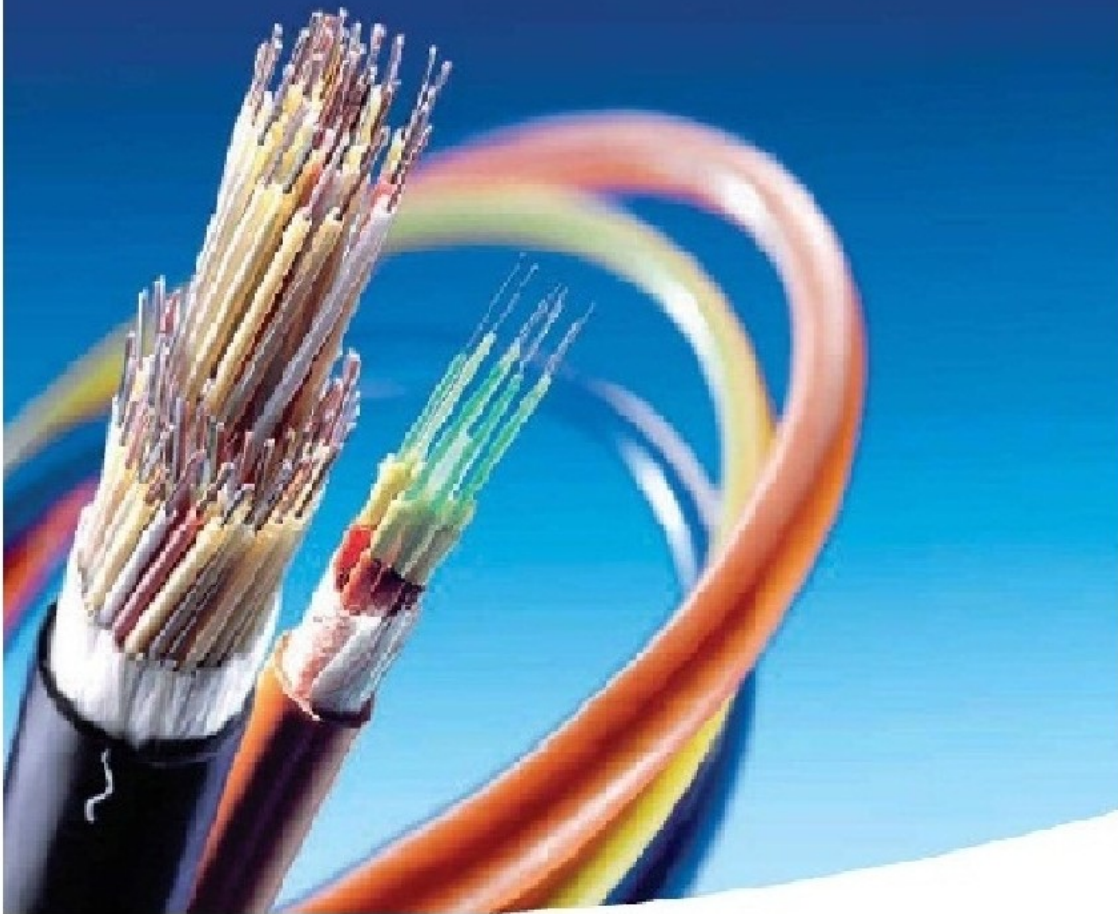
Radio System

Radio systems are used for short distance, cheap and easy to tap. Radio is the radiation (wireless transmission) of electromagnetic signals through the atmosphere or free space.

Information, such as sound, is carried by systematically changing (modulating) some property of the radiated waves, such as their amplitude, frequency, phase, or pulse width. When radio waves strike an electrical conductor, the oscillating fields induce an alternating current in the conductor. The information in the waves can be extracted and transformed back into its original form.

Fiber Optics

Fiber Optic Cables



Microwave radio system

Microwave transmission refers to the technology of transmitting information or energy by the use of radio waves whose wavelengths are conveniently measured in small numbers of centimeter; these are called microwaves.

Microwaves are widely used for point-to-point communications because their small wavelength allows conveniently-sized antennas to direct them in narrow beams, which can be pointed directly at the receiving antenna. This allows nearby microwave equipment to use the same frequencies without interfering with each other, as lower frequency radio waves do. Another advantage is that the high frequency of microwaves gives the microwave band a very large information-carrying capacity; the microwave band has a bandwidth 30 times that of all the rest of the radio spectrum below it. A disadvantage is that microwaves are limited to line of sight propagation; they cannot pass around hills or mountains as lower frequency radio waves can.

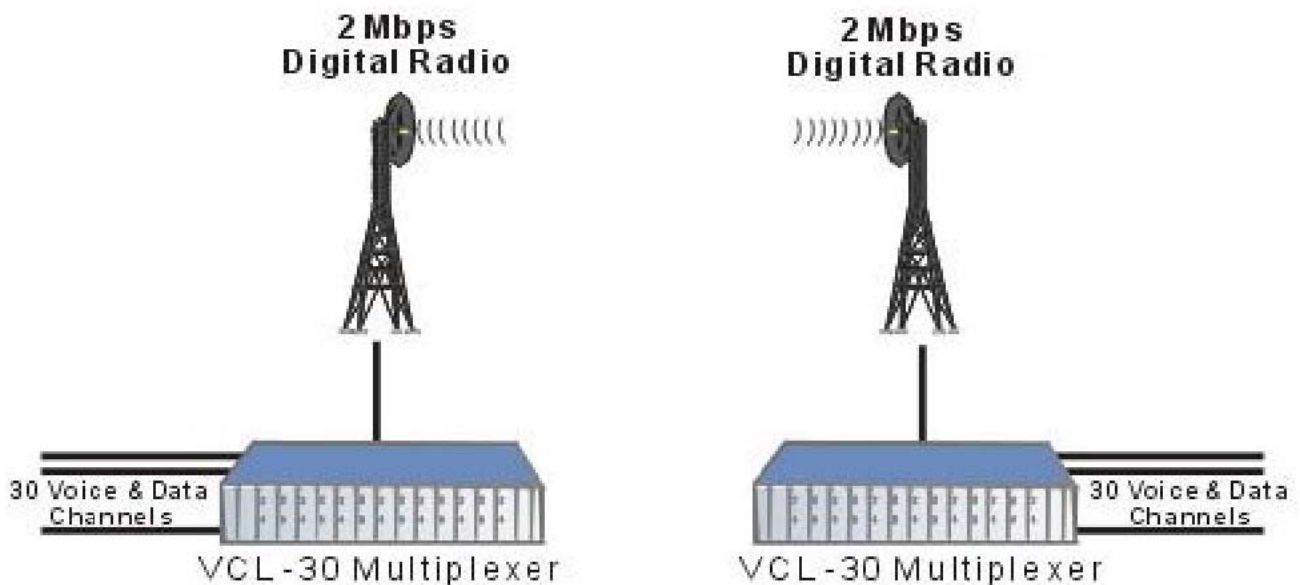
Microwave radio transmission is commonly used in point-to-point communication systems on the surface of the Earth, in satellite communications, and in deep space radio communications. Other parts of the microwave radio band are used for radars, radio navigation systems, sensor systems, and radio astronomy.

Microwave radio systems are carriers for voice data signal, cheap and easy to tap.

Microwave Radio System

VCL-30 E1, 2Mbps Multiplexer

Digital Microwave Radio Link



Satellite Radio Link

Satellite radio is a radio service broadcast from satellites primarily to cars, with the signal broadcast nationwide, across a much wider geographical area than terrestrial radio stations. It is available by subscription, mostly commercial free, and offers subscribers more stations and a wider variety of programming

options than terrestrial radio.

Satellite radio link uses transponder to send information and easy to tap.

The following answers are incorrect:

Copper Cable- Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data.

Radio System - Radio systems are used for short distance, cheap and easy to tap. Satellite Radio Link - Satellite radio link uses transponder to send information and easy to tap.

CISA review manual 2014 page number 265 &

Official ISC2 guide to CISSP CBK 3rd Edition Page number 233

QUESTION 26

Why would a database be renormalized?

- A. To ensure data integrity
- B. To increase processing efficiency
- C. To prevent duplication of data
- D. To save storage space

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation A database is renormalized when there is a need to improve processing efficiency.

There is, however, a risk to data integrity when this occurs. Since it implies the introduction of duplication, it will not likely allow saving of storage space.

Reference: Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, Chapter 3: Technical Infrastructure and Operational Practices (page 109).

QUESTION 27

Which of the following is not a common method of multiplexing data?

- A. Analytical multiplexing
- B. Time-division multiplexing
- C. Asynchronous time-division multiplexing
- D. Frequency division multiplexing

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Generally, the methods for multiplexing data include the following:

Time-division multiplexing (TDM): information from each data channel is allocated bandwidth based on pre- assigned time slots, regardless of whether there is data to transmit. Asynchronous time-division multiplexing (ATDM): information from data channels is allocated bandwidth as

needed, via dynamically assigned time slots.

Frequency division multiplexing (FDM): information from each data channel is allocated bandwidth based on the signal frequency of the traffic.

Statistical multiplexing: Bandwidth is dynamically allocated to any data channels that have information to transmit.

Reference: Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, Chapter 3: Technical Infrastructure and Operational Practices (page 114).

QUESTION 28

Which of the following ISO/OSI layers performs transformations on data to provide a standardized application interface and to provide common communication services such as encryption?

- A. Application layer
- B. Session layer
- C. Presentation layer
- D. Transport layer

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation The presentation layer (ISO/OSI layer 6) performs transformations on data to provide a standardized application interface and to provide common communication services such as encryption, text compression and reformatting. The function of the presentation layer is to ensure that the format of the data submitted by the application layer conforms to the applicable network standard. Reference: Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, Chapter 3: Technical Infrastructure and Operational Practices (page 119).

QUESTION 29

Which of the following is NOT a defined ISO basic task related to network management?

- A. Fault management
- B. Accounting resources
- C. Security management
- D. Communications management

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Fault management: Detects the devices that present some kind of fault. Configuration management: Allows users to know, define and change remotely the configuration of any device. Accounting resources: Holds the records of the resource usage in the WAN. Performance management: Monitors usage levels and sets alarms when a threshold has been surpassed. Security management: Detects suspicious traffic or users and generates alarms accordingly.

Reference: Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, Chapter 3: Technical Infrastructure and Operational Practices (page 137).

QUESTION 30

What is the most effective means of determining that controls are functioning properly within an operating system?

- A. Interview with computer operator
- B. Review of software control features and/or parameters
- C. Review of operating system manual
- D. Interview with product vendor

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Various operating system software products provide parameters and options for the tailoring of the system and activation of features such as activity logging. Parameters are important in determining how a system runs because they allow a standard piece of software to be customized to diverse environments. The reviewing of software control features and/or parameters is the most effective means of determining how controls are functioning within an operating system and of assessing and operating system's integrity.

The operating system manual should provide information as to what settings can be used but will not likely give any hint as to how parameters are actually set. The product vendor and computer operator are not necessarily aware of the detailed setting of all parameters.

The review of software control features and/or parameters would be part of your security audit. A security audit is typically performed by an independent third party to the management of the system. The audit determines the degree with which the required controls are implemented.

A security review is conducted by the system maintenance or security personnel to discover vulnerabilities within the system. A vulnerability occurs when policies are not followed, misconfigurations are present, or flaws exist in the hardware or software of the system. System reviews are sometimes referred to as a vulnerability assessment.

Schneider, Andrew (2013-04-15). Official (ISC)2 Guide to the CISSP CBK, Third Edition: Security Operations, Page 1054, for users with the Kindle edition look at Locations 851-855 and

Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, Chapter 3: Technical Infrastructure and Operational Practices (page 102).

QUESTION 31

Which of the following characteristics pertaining to databases is not true?

- A. A data model should exist and all entities should have a significant name.
- B. Justifications must exist for normalized data.
- C. No NULLs should be allowed for primary keys.
- D. All relations must have a specific cardinality.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Justifications should be provided when data is renormalized, not when it is normalized, because it introduces risk of data inconsistency. Renormalization is usually introduced for performance purposes.

Reference: Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, Chapter 3: Technical Infrastructure and Operational Practices (page 108).

QUESTION 32

Which of the following is the BEST way to detect software license violations?

- A. Implementing a corporate policy on copyright infringements and software use.
- B. Requiring that all PCs be diskless workstations.
- C. Installing metering software on the LAN so applications can be accessed through the metered software.
- D. Regularly scanning PCs in use to ensure that unauthorized copies of software have not been loaded on the PC.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation The best way to prevent and detect software license violations is to regularly scan used PCs, either from the LAN or directly, to ensure that unauthorized copies of software have not been loaded on the PC.

Other options are not detective.

A corporate policy is not necessarily enforced and followed by all employees. Software can be installed from other means than floppies or CD-ROMs (from a LAN or even downloaded from the Internet) and software metering only concerns applications that are registered.

Reference: Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, Chapter 3: Technical Infrastructure and Operational Practices (page 108).

QUESTION 33

For an auditor, it is very important to understand the different forms of project organization and their implication in the control of project management activities. In which of the following project organization form is management authority shared between the project manager and the department head?

- A. Influence project organization
- B. Pure project organization
- C. Matrix project organization
- D. Forward project organization

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation For CISA exam you should know the information below about Project Organizational Forms.

Three major forms of organizational alignment for project management within business organization are observe:

Influence project organization The project manager has only a staff function without formal management authority. The project manager is only allowed to advise peers and team members as to which activities should be completed.

Pure project organization The project manager has formal authority over those taking part in the project. Often this is bolstered by providing a special working area for the project team that is separated from their normal office space.

Matrix project organization Management authority is shared between the project manager and the department head.

Request for the major project should be submitted to and prioritize by the IS steering committee. A project manager should be identified and appointed by the IS steering committee. The project manager, who need not be an IS staff member

The following were incorrect answers:

Influence project organization The project manager has only a staff function without formal management authority. The project manager is only allowed to advise peers and team members as to which activities should be completed.

Pure project organization The project manager has formal authority over those taking part in the project. Often this is bolstered by providing a special working area for the project team that is separated from their normal office space.

Forward project organization- Not a valid type of project organization form.
CISA review manual 2014 Page number 148

QUESTION 34

Who provides the funding to the project and works closely with the project manager to define critical success factor (CSF)?

- A. Project Sponsor
- B. Security Officer
- C. User Management
- D. Senior Management

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Project sponsor provides funding for the project and works closely with the project manager to define critical success factor(CSFs) and metrics for measuring the success of the project. It is crucial that success is translated to measurable and quantifiable terms. Data and application ownership are assigned to a project sponsor. A project sponsor is typically the senior manager in charge of the primary business unit that the application will support.

For the CISA exam you should know the information below about roles and responsibilities of groups/ individuals that may be involved in the development process are summarized below:

Senior Management Demonstrate commitment to the project and approves the necessary resources to complete the project. This commitment from senior management helps ensure involvement by those needed to complete the project.

User Management Assumes ownership of the project and resulting system, allocates qualified representatives to the team, and actively participates in business process redesign, system requirement definitions, test case development, acceptance testing and user training. User management is concerned primarily with the following questions:

Are the required functions available in the software?
How reliable is the software?
How effective is the software?
Is the software easy to use?
How easy is to transfer or adapt old data from preexisting software to this environment?

Is it possible to add new functions?
Does it meet regulatory requirement?

Project Steering Committee Provides overall directions and ensures appropriate representation of the major stakeholders in the project's outcome. The project steering committee is ultimately responsible for all deliverables, project costs and schedules. This committee should be comprised of senior representative from each business area that will be significantly impacted by the proposed new system or system modifications.

System Development Management Provides technical support for hardware and software environment by developing, installing and operating the requested system.

Project Manager Provides day-to-day management and leadership of the project, ensures that project activities remain in line with the overall directions, ensures appropriate representation of the affected departments, ensures that the project adheres local standards, ensures that deliverable meet the quality expectation of key stakeholder, resolve interdepartmental conflict, and monitors and controls cost of the project timetables.

Project Sponsor Project sponsor provides funding for the project and works closely with the project manager to define critical success factor(CSFs) and metrics for measuring the success of the project. It is crucial that success is translated to measurable and quantifiable terms. Data and application ownership are assigned to a project sponsor. A project sponsor is typically the senior manager in charge of the primary business unit that the application will support.

System Development Project Team Completes assigned tasks, communicates effectively with user by actively involving them in the development process, works according to local standards, and advise the project manager of necessary plan deviations.

User Project Team Completes assigned tasks, communicate effectively with the system developers by actively involving themselves in the development process as Subject Matter Expert (SME) and works according to local standards, and advise the project manager of expected and actual project deviations.

Security Officer Ensures that system controls and supporting processes provides an effective level of protection, based on the data classification set in accordance with corporate security policies and procedures:
consult throughout the life cycle on appropriate security measures that should be incorporated into the system.

Quality Assurance Personnel who review result and deliverables within each phase and at the end of each phase, and confirm compliance with requirements. Their objective is to ensure that the quality of the project by measuring adherence of the project staff to the organization's software development life cycle (SDLC), advise on the deviation and propose recommendation for process improvement or greater control points when deviation occur.

The following were incorrect answers:

Security Officer Ensures that system controls and supporting processes provides an effective level of protection, based on the data classification set in accordance with corporate security policies and procedures:
consult throughout the life cycle on appropriate security measures that should be incorporated into the system.

User Management Assumes ownership of the project and resulting system, allocates qualified representatives to the team, and actively participates in business process redesign, system requirement definitions, test case development, acceptance testing and user training.

Senior Management Demonstrate commitment to the project and approves the necessary resources to complete the project. This commitment from senior management helps ensure involvement by those needed to complete the project.
CISA review manual 2014 Page number 150

QUESTION 35

Who is responsible for ensuring that system controls and supporting processes provides an effective level of protection, based on the data classification set in accordance with corporate security policies and procedures?

- A. Project Sponsor
- B. Security Officer
- C. User Management
- D. Senior Management

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Security Officer ensures that system controls and supporting processes provides an effective level of protection, based on the data classification set in accordance with corporate security policies and procedures:
consult throughout the life cycle on appropriate security measures that should be incorporated into the system. For the CISA exam you should know the information below about roles and responsibilities of groups/ individuals that may be involved in the development process are summarized below:

Senior Management Demonstrate commitment to the project and approves the necessary resources to complete the project. This commitment from senior management helps ensure involvement by those needed to complete the project.

User Management Assumes ownership of the project and resulting system, allocates qualified representatives to the team, and actively participates in business process redesign, system requirement definitions, test case development, acceptance testing and user training. User management is concerned primarily with the following questions:

Are the required functions available in the software?
How reliable is the software?
How effective is the software?
Is the software easy to use?
How easy is to transfer or adapt old data from preexisting software to this environment?
Is it possible to add new functions?
Does it meet regulatory requirement?

Project Steering Committee Provides overall directions and ensures appropriate representation of the major stakeholders in the project's outcome. The project steering committee is ultimately responsible for all deliverables, project costs and schedules. This committee should be comprised of senior representative from each business area that will be significantly impacted by the proposed new system or system modifications.

System Development Management Provides technical support for hardware and software environment by developing, installing and operating the requested system.

Project Manager Provides day-to-day management and leadership of the project, ensures that project activities remain in line with the overall directions, ensures appropriate representation of the affected departments, ensures that the project adheres local standards, ensures that deliverable meet the quality expectation of key stakeholder, resolve interdepartmental conflict, and monitors and controls cost of the project timetables.

Project Sponsor Project sponsor provides funding for the project and works closely with the project manager

to define critical success factor(CSFs) and metrics for measuring the success of the project. It is crucial that success is translated to measurable and quantifiable terms. Data and application ownership are assigned to a project sponsor. A project sponsor is typically the senior manager in charge of the primary business unit that the application will support.

System Development Project Team Completes assigned tasks, communicates effectively with user by actively involving them in the development process, works according to local standards, and advise the project manager of necessary plan deviations.

User Project Team Completes assigned tasks, communicate effectively with the system developers by actively involving themselves in the development process as Subject Matter Expert (SME) and works according to local standards, and advise the project manager of expected and actual project deviations.

Security Officer Ensures that system controls and supporting processes provides an effective level of protection, based on the data classification set in accordance with corporate security policies and procedures: consult throughout the life cycle on appropriate security measures that should be incorporated into the system.

Quality Assurance Personnel who review result and deliverables within each phase and at the end of each phase, and confirm compliance with requirements. Their objective is to ensure that the quality of the project by measuring adherence of the project staff to the organization's software development life cycle (SDLC), advise on the deviation and propose recommendation for process improvement or greater control points when deviation occur.

The following were incorrect answers:

Project Sponsor Project sponsor provides funding for the project and works closely with the project manager to define critical success factor(CSFs) and metrics for measuring the success of the project. It is crucial that success is translated to measurable and quantifiable terms. Data and application ownership are assigned to a project sponsor. A project sponsor is typically the senior manager in charge of the primary business unit that the application will support.

User Management Assumes ownership of the project and resulting system, allocates qualified representatives to the team, and actively participates in business process redesign, system requirement definitions, test case development, acceptance testing and user training.

Senior Management Demonstrate commitment to the project and approves the necessary resources to complete the project. This commitment from senior management helps ensure involvement by those needed to complete the project.
CISA review manual 2014 Page number 150

QUESTION 36

Who is responsible for reviewing the result and deliverables within and at the end of each phase, as well as confirming compliance with requirements?

- A. Project Sponsor
- B. Quality Assurance
- C. User Management
- D. Senior Management

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Quality Assurance personnel review result and deliverables within each phase and at the end of each phase, and confirm compliance with requirements. Their objective is to ensure that the quality of the project by measuring adherence of the project staff to the organization's software development life cycle (SDLC), advise on the deviation and propose recommendation for process improvement or greater control points when deviation occur.

For CISA exam you should know below information about roles and responsibilities of groups/individuals that may be involved in the development process are summarized below:

Senior Management Demonstrate commitment to the project and approves the necessary resources to complete the project. This commitment from senior management helps ensure involvement by those needed to complete the project.

User Management Assumes ownership of the project and resulting system, allocates qualified representatives to the team, and actively participates in business process redesign, system requirement definitions, test case development, acceptance testing and user training. User management is concerned primarily with the following questions:

Are the required functions available in the software?
How reliable is the software?
How effective is the software?
Is the software easy to use?
How easy is to transfer or adapt old data from preexisting software to this environment? Is it possible to add new functions?
Does it meet regulatory requirement?

Project Steering Committee Provides overall directions and ensures appropriate representation of the major stakeholders in the project's outcome. The project steering committee is ultimately responsible for all deliverables, project costs and schedules. This committee should be comprised of senior representative from each business area that will be significantly impacted by the proposed new system or system modifications.

System Development Management Provides technical support for hardware and software environment by developing, installing and operating the requested system.

Project Manager Provides day-to-day management and leadership of the project, ensures that project activities remain in line with the overall directions, ensures appropriate representation of the affected departments, ensures that the project adheres local standards, ensures that deliverable meet the quality expectation of key stakeholder, resolve interdepartmental conflict, and monitors and controls cost of the project timetables.

Project Sponsor Project sponsor provides funding for the project and works closely with the project manager to define critical success factor(CSFs) and metrics for measuring the success of the project. It is crucial that success is translated to measurable and quantifiable terms. Data and application ownership are assigned to a project sponsor. A project sponsor is typically the senior manager in charge of the primary business unit that the application will support.

System Development Project Team Completes assigned tasks, communicates effectively with user by actively involving them in the development process, works according to local standards, and advise the project manager of necessary plan deviations.

User Project Team Completes assigned tasks, communicate effectively with the system developers by actively involving themselves in the development process as Subject Matter Expert (SME) and works according to local standards, and advise the project manager of expected and actual project deviations.

Security Officer Ensures that system controls and supporting processes provides an effective level of protection, based on the data classification set in accordance with corporate security policies and procedures: consult throughout the life cycle on appropriate security measures that should be incorporated into the system.

Quality Assurance Personnel who review result and deliverables within each phase and at the end of each phase, and confirm compliance with requirements. Their objective is to ensure that the quality of the project by measuring adherence of the project staff to the organization's software development life cycle (SDLC),

advise on the deviation and propose recommendation for process improvement or greater control points when deviation occur.

The following were incorrect answers:

Project Sponsor Project sponsor provides funding for the project and works closely with the project manager to define critical success factor(CSFs) and metrics for measuring the success of the project. It is crucial that success is translated to measurable and quantifiable terms. Data and application ownership are assigned to a project sponsor. A project sponsor is typically the senior manager in charge of the primary business unit that the application will support.

User Management Assumes ownership of the project and resulting system, allocates qualified representatives to the team, and actively participates in business process redesign, system requirement definitions, test case development, acceptance testing and user training.

Senior Management Demonstrate commitment to the project and approves the necessary resources to complete the project. This commitment from senior management helps ensure involvement by those needed to complete the project.
CISA review manual 2014 Page number 150

QUESTION 37

Who is responsible for providing technical support for the hardware and software environment by developing, installing and operating the requested system?

- A. System Development Management
- B. Quality Assurance
- C. User Management
- D. Senior Management

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation System Development Management provides technical support for hardware and software environment by developing, installing and operating the requested system.

For the CISA exam you should know the information below about roles and responsibilities of groups/ individuals that may be involved in the development process are summarized below:

Senior Management Demonstrate commitment to the project and approves the necessary resources to complete the project. This commitment from senior management helps ensure involvement by those needed to complete the project.

User Management Assumes ownership of the project and resulting system, allocates qualified representatives to the team, and actively participates in business process redesign, system requirement definitions, test case development, acceptance testing and user training. User management is concerned primarily with the following questions:

Are the required functions available in the software?

How reliable is the software?

How effective is the software?

Is the software easy to use?

How easy is to transfer or adapt old data from preexisting software to this environment? Is it possible to add new functions?

Does it meet regulatory requirement?

Project Steering Committee Provides overall directions and ensures appropriate representation of the major stakeholders in the project's outcome. The project steering committee is ultimately responsible for all deliverables, project costs and schedules. This committee should be comprised of senior representative from each business area that will be significantly impacted by the proposed new system or system modifications.

System Development Management Provides technical support for hardware and software environment by developing, installing and operating the requested system.

Project Manager Provides day-to-day management and leadership of the project, ensures that project activities remain in line with the overall directions, ensures appropriate representation of the affected departments, ensures that the project adheres local standards, ensures that deliverable meet the quality expectation of key stakeholder, resolve interdepartmental conflict, and monitors and controls cost of the project timetables.

Project Sponsor Project sponsor provides funding for the project and works closely with the project manager to define critical success factor(CSFs) and metrics for measuring the success of the project. It is crucial that success is translated to measurable and quantifiable terms. Data and application ownership are assigned to a project sponsor. A project sponsor is typically the senior manager in charge of the primary business unit that the application will support.

System Development Project Team Completes assigned tasks, communicates effectively with user by actively involving them in the development process, works according to local standards, and advise the project manager of necessary plan deviations.

User Project Team Completes assigned tasks, communicate effectively with the system developers by actively involving themselves in the development process as Subject Matter Expert (SME) and works according to local standards, and advise the project manager of expected and actual project deviations.

Security Officer Ensures that system controls and supporting processes provides an effective level of protection, based on the data classification set in accordance with corporate security policies and procedures:
consult throughout the life cycle on appropriate security measures that should be incorporated into the system.

Quality Assurance Personnel who review result and deliverables within each phase and at the end of each phase, and confirm compliance with requirements. Their objective is to ensure that the quality of the project by measuring adherence of the project staff to the organization's software development life cycle (SDLC), advise on the deviation and propose recommendation for process improvement or greater control points when deviation occur.

The following were incorrect answers:

Quality Assurance Personnel who review result and deliverables within each phase and at the end of each phase, and confirm compliance with requirements. Their objective is to ensure that the quality of the project by measuring adherence of the project staff to the organization's software development life cycle (SDLC), advise on the deviation and propose recommendation for process improvement or greater control points when deviation occur.

User Management Assumes ownership of the project and resulting system, allocates qualified representatives to the team, and actively participates in business process redesign, system requirement definitions, test case development, acceptance testing and user training.

Senior Management Demonstrate commitment to the project and approves the necessary resources to complete the project. This commitment from senior management helps ensure involvement by those needed to complete the project.
CISA review manual 2014 Page number 150

QUESTION 38

Which of the following factor is LEAST important in the measurement of critical success factors of productivity in the SDLC phases?

- A. Dollar Spent per use

- B. Number of transactions per month
- C. Number of transactions per user
- D. Number of occurrences of fraud/misuse detection

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation The LEAST is the keyword used in this question, You need to find out a LEAST important factor in the measurement of the productivity.

For the CISA exam you should know the table below which contains information about measurement of a critical success factor.

Measurement of Critical Success Factors

Productivity

Dollars spent per use

Number of transactions per month

Number of transactions per user

Quality

Number of discrepancies

Number of disputes

Number of occurrences of fraud/misuse detection

Economic value

Total processing time reduction

Momentary value of administration costs

Customer service

Turnaround time for customer question handling

Frequency of useful communication to user.

The following were incorrect answers:

The other options presented are more important in the measurement of critical success factor of the productivity.

CISA review manual 2014 Page number 159

QUESTION 39

Which of the following statement correctly describes the difference between QAT and UAT?

- A. QAT focuses on technical aspect of the application and UAT focuses on functional aspect of the application
- B. UAT focuses on technical aspect of the application and QAT focuses on functional aspect of the application
- C. UAT and QAT both focuses on functional aspect of the application
- D. UAT and QAT both focuses on technical aspect of the application

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Final Acceptance Testing -It has two major parts: Quality Assurance Testing(QAT) focusing on the technical aspect of the application and User acceptance testing focusing on functional aspect of the application.

For CISA exam you should know below types of testing:

Unit Testing The testing of an individual program or module. Unit testing uses set of test cases that focus on control structure of procedural design. These tests ensure internal operation of the programs according to the specification.

Interface or integration testing A hardware or software test that evaluates the connection of two or more components that pass information from one area to another. The objective is to take unit tested module and build an integrated structure dictated by design. The term integration testing is also referred to tests that verify and validate functioning of the application under test with other systems, where a set of data is transferred from one system to another.

System Testing A series of tests designed to ensure that modified programs, objects, database schema, etc , which collectively constitute a new or modified system, function properly. These test procedures are often performed in a non-production test/development environment by software developers designated as a test team. The following specific analysis may be carried out during system testing.

Recovery Testing Checking the system's ability to recover after a software or hardware failure.

Security Testing Making sure the modified/new system includes provisions for appropriate access control and does not introduce any security holes that might compromise other systems.

Load Testing Testing an application with large quantities of data to evaluate its performance during peak hour.

Volume testing Studying the impact on the application by testing with an incremental volume of records to determine the maximum volume of records that application can process.

Stress Testing Studying the impact on the application by testing with an incremental number of concurrent users/services on the application to determine maximum number of concurrent user/service the application can process.

Performance Testing Comparing the system performance to other equivalent systems using well defined benchmarks.

Final Acceptance Testing It has two major parts: Quality Assurance Testing(QAT) focusing on the technical aspect of the application and User acceptance testing focusing on functional aspect of the application. QAT focuses on documented specifications and the technology employed. It verifies that application works as documented by testing the logical design and the technology itself. It also ensures that the application meet the documented technical specifications and deliverables. QAT is performed primarily by IS department. The participation of end user is minimal and on request. QAT does not focus on functionality testing. UAT supports the process of ensuring that the system is production ready and satisfies all documented requirements. The methods include:
Definition of test strategies and procedure.

Design of test cases and scenarios

Execution of the tests.

Utilization of the result to verify system readiness.

Acceptance criteria are defined criteria that a deliverable must meet to satisfy the predefined needs of the user. A UAT plan must be documented for the final test of the completed system. The tests are written from a user's perspective and should test the system in a manner as close to production possible.

The following were incorrect answers:

The other presented options incorrectly describe the difference between QAT and UAT CISA review manual 2014 Page number 166

QUESTION 40

Which of the following type of testing uses a set of test cases that focus on control structure of the procedural design?

- A. Interface testing
- B. Unit Testing
- C. System Testing
- D. Final acceptance testing

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation Unit testing is the testing of an individual program or module. Unit testing uses set of test cases that focus on control structure of procedural design. These tests ensure internal operation of the programs according to the specification.

For CISA exam you should know below types of testing:

Unit Testing The testing of an individual program or module. Unit testing uses set of test cases that focus on control structure of procedural design. These tests ensure internal operation of the programs according to the specification.

Interface or integration testing A hardware or software test that evaluates the connection of two or more components that pass information from one area to another. The objective is to take unit tested module and build an integrated structure dictated by design. The term integration testing is also referred to tests that verify and validate functioning of the application under test with other systems, where a set of data is transferred from one system to another.

System Testing A series of tests designed to ensure that modified programs, objects, database schema, etc., which collectively constitute a new or modified system, function properly. These test procedures are often performed in a non-production test/development environment by software developers designated as a test team. The following specific analysis may be carried out during system testing.

Recovery Testing Checking the system's ability to recover after a software or hardware failure.

Security Testing Making sure the modified/new system includes provisions for appropriate access control and does not introduce any security holes that might compromise other systems.

Load Testing Testing an application with large quantities of data to evaluate its performance during peak hour.

Volume testing Studying the impact on the application by testing with an incremental volume of records to determine the maximum volume of records that application can process.

Stress Testing Studying the impact on the application by testing with an incremental number of concurrent users/services on the application to determine maximum number of concurrent user/service the application can process.

Performance Testing Comparing the system performance to other equivalent systems using well defined benchmarks.

Final Acceptance Testing It has two major parts: Quality Assurance Testing(QAT) focusing on the technical aspect of the application and User acceptance testing focusing on functional aspect of the application. QAT focuses on documented specifications and the technology employed. It verifies that application works as documented by testing the logical design and the technology itself. It also ensures that the application meet the documented technical specifications and deliverables. QAT is performed primarily by IS department. The participation of end user is minimal and on request. QAT does not focus on functionality testing. UAT supports the process of ensuring that the system is production ready and satisfies all documented requirements. The methods include:

Definition of test strategies and procedure.

Design of test cases and scenarios

Execution of the tests.

Utilization of the result to verify system readiness.

Acceptance criteria are defined criteria that a deliverable must meet to satisfy the predefined needs of the user. A UAT plan must be documented for the final test of the completed system. The tests are written from a user's perspective and should test the system in a manner as close to production possible.

The following were incorrect answers:

Interface or integration testing A hardware or software test that evaluates the connection of two or more components that pass information from one area to another. The objective is to take unit tested module and build an integrated structure dictated by design. The term integration testing is also referred to tests that verify and validate functioning of the application under test with other systems, where a set of data is transferred from one system to another.

System Testing A series of tests designed to ensure that modified programs, objects, database schema, etc., which collectively constitute a new or modified system, function properly. These test procedures are often performed in a non-production test/development environment by software developers designated as a test team.

Final Acceptance Testing During this testing phase the defined methods of testing to apply should be incorporated into the organization's QA methodology. CISA review manual 2014 Page number 166

QUESTION 41

Which of the following type of testing has two major categories: QAT and UAT?

- A. Interface testing
- B. Unit Testing
- C. System Testing
- D. Final acceptance testing

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 42

Which of the following type of testing validate functioning of the application under test with other system, where a set of data is transferred from one system to another?

- A. Interface testing
- B. Unit Testing
- C. System Testing
- D. Final acceptance testing

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Interface or integration testing is a hardware or software test that evaluates the connection of two or more components that pass information from one area to another. The objective is to take unit tested module and build an integrated structure dictated by design. The term integration testing is also referred to tests that verify and validate functioning of the application under test with other systems, where a set of data is transferred from one system to another.

For CISA exam you should know below types of testing:

Unit Testing The testing of an individual program or module. Unit testing uses set of test cases that focus on control structure of procedural design. These tests ensure internal operation of the programs according to the specification.

Interface or integration testing A hardware or software test that evaluates the connection of two or more components that pass information from one area to another. The objective is to take unit tested module and build an integrated structure dictated by design. The term integration testing is also referred to tests that verify and validate functioning of the application under test with other systems, where a set of data is transferred from one system to another.

System Testing A series of tests designed to ensure that modified programs, objects, database schema, etc., which collectively constitute a new or modified system, function properly. These test procedures are often performed in a non-production test/development environment by software developers designated as a test team. The following specific analysis may be carried out during system testing.

Recovery Testing Checking the system's ability to recover after a software or hardware failure.

Security Testing Making sure the modified/new system includes provisions for appropriate access control and does not introduce any security holes that might compromise other systems.

Load Testing Testing an application with large quantities of data to evaluate its performance during peak hour.

Volume testing Studying the impact on the application by testing with an incremental volume of records to determine the maximum volume of records that application can process.

Stress Testing Studying the impact on the application by testing with an incremental number of concurrent users/services on the application to determine maximum number of concurrent user/service the application can process.

Performance Testing Comparing the system performance to other equivalent systems using well defined benchmarks.

Final Acceptance Testing It has two major parts: Quality Assurance Testing(QAT) focusing on the technical aspect of the application and User acceptance testing focusing on functional aspect of the application. QAT focuses on documented specifications and the technology employed. It verifies that application works as documented by testing the logical design and the technology itself. It also ensures that the application meets the documented technical specifications and deliverables. QAT is performed primarily by IS department. The participation of end user is minimal and on request. QAT does not focus on functionality testing. UAT supports the process of ensuring that the system is production ready and satisfies all documented requirements. The methods include:

Definition of test strategies and procedure.

Design of test cases and scenarios

Execution of the tests.

Utilization of the result to verify system readiness.

Acceptance criteria are defined criteria that a deliverable must meet to satisfy the predefined needs of the user. A UAT plan must be documented for the final test of the completed system. The tests are written from a user's perspective and should test the system in a manner as close to production possible.

The following were incorrect answers:

Unit Testing The testing of an individual program or module. Unit testing uses set of test cases that focus on control structure of procedural design. These tests ensure internal operation of the programs according to the specification.

System Testing A series of tests designed to ensure that modified programs, objects, database schema, etc., which collectively constitute a new or modified system, function properly. These test procedures are often performed in a non-production test/development environment by software developers designated as a test team.

Final Acceptance Testing During this testing phase the defined methods of testing to apply should be incorporated into the organization's QA methodology.

CISA review manual 2014 Page number 166

QUESTION 43

Identify the INCORRECT statement from below mentioned testing types

- A. **Recovery Testing** Making sure the modified/new system includes provisions for appropriate access control and does not introduce any security holes that might compromise other systems
- B. **Load Testing** Testing an application with large quantities of data to evaluate its performance during peak hour
- C. **Volume testing** Studying the impact on the application by testing with an incremental volume of records to determine the maximum volume of records that application can process
- D. **Stress Testing** Studying the impact on the application by testing with an incremental number of concurrent users/services on the application to determine maximum number of concurrent user/service the application can process

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation The word INCORRECT is the keyword used in this question. You need to find out the incorrect option specified above. The term recovery testing is incorrectly defined in the above options. The correct description of recovery testing is: Recovery Testing Checking the system's ability to recover after a software or hardware failure

For CISA exam you should know below types of testing:

Unit Testing The testing of an individual program or module. Unit testing uses set of test cases that focus on control structure of procedural design. These tests ensure internal operation of the programs according to the specification.

Interface or integration testing A hardware or software test that evaluates the connection of two or more components that pass information from one area to another. The objective is to take unit tested module and build an integrated structure dictated by design. The term integration testing is also referred to tests that verify and validate functioning of the application under test with other systems, where a set of data is transferred from one system to another.

System Testing A series of tests designed to ensure that modified programs, objects, database schema, etc., which collectively constitute a new or modified system, function properly. These test procedures are often performed in a non-production test/development environment by software developers designated as a test team. The following specific analysis may be carried out during system testing.

Recovery Testing Checking the system's ability to recover after a software or hardware failure.

Security Testing Making sure the modified/new system includes provisions for appropriate access control and does not introduce any security holes that might compromise other systems. **Load Testing** Testing an application with large quantities of data to evaluate its performance during peak hour.

Volume testing Studying the impact on the application by testing with an incremental volume of records to determine the maximum volume of records that application can process.

Stress Testing Studying the impact on the application by testing with an incremental number of concurrent users/services on the application to determine maximum number of concurrent user/service the application can process.

Performance Testing Comparing the system performance to other equivalent systems using well defined benchmarks.

Final Acceptance Testing It has two major parts: Quality Assurance Testing(QAT) focusing on the technical aspect of the application and User acceptance testing focusing on functional aspect of the application. QAT focuses on documented specifications and the technology employed. It verifies that application works as documented by testing the logical design and the technology itself. It also ensures that the application meet the documented technical specifications and deliverables. QAT is performed primarily by IS department. The participation of end user is minimal and on request. QAT does not focus on functionality testing. UAT supports the process of ensuring that the system is production ready and satisfies all documented requirements. The methods include:

Definition of test strategies and procedure.

Design of test cases and scenarios

Execution of the tests.

Utilization of the result to verify system readiness.

Acceptance criteria are defined criteria that a deliverable must meet to satisfy the predefined needs of the user. A UAT plan must be documented for the final test of the completed system. The tests are written from a user's perspective and should test the system in a manner as close to production possible.

The following were incorrect answers:

The other options presented contains valid definitions.

CISA review manual 2014 Page number 166

QUESTION 44

Which of the following is the process of repeating a portion of a test scenario or test plan to ensure that

changes in information system have not introduced any errors?

- A. Parallel Test
- B. Black box testing
- C. Regression Testing
- D. Pilot Testing

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Regression testing is the process of rerunning a portion of a test scenario or test plan to ensure that changes or corrections have not introduced new errors. The data used in regression testing should be same as original data.

For CISA exam you should know below mentioned types of testing

Alpha and Beta Testing An alpha version is early version is an early version of the application system submitted to the internal user for testing. The alpha version may not contain all the features planned for the final version. Typically, software goes to two stages testing before it consider finished. The first stage is called alpha testing is often performed only by the user within the organization developing the software. The second stage is called beta testing, a form of user acceptance testing, generally involves a limited number of external users. Beta testing is the last stage of testing, and normally involves real world exposure, sending the beta version of the product to independent beta test sites or offering it free to interested user.

Pilot Testing A preliminary test that focuses on specific and predefined aspect of a system. It is not meant to replace other testing methods, but rather to provide a limited evaluation of the system. Proof of concept are early pilot tests usually over interim platform and with only basic functionalities.

White box testing Assess the effectiveness of a software program logic. Specifically, test data are used in determining procedural accuracy or conditions of a program's specific logic path. However, testing all possible logical path in large information system is not feasible and would be cost prohibitive, and therefore is used on selective basis only.

Black Box Testing An integrity based form of testing associated with testing components of an information system's "functional" operating effectiveness without regards to any specific internal program structure. Applicable to integration and user acceptance testing.

Function/validation testing It is similar to system testing but it is often used to test the functionality of the system against the detailed requirements to ensure that the software that has been built is traceable to customer requirements.

Regression Testing The process of rerunning a portion of a test scenario or test plan to ensure that changes or corrections have not introduced new errors. The data used in regression testing should be same as original data.

Parallel Testing This is the process of feeding test data into two systems the modified system and an alternative system and comparing the result.

Sociability Testing The purpose of these tests is to confirm that new or modified system can operate in its target environment without adversely impacting existing system. This should cover not only platform that will perform primary application processing and interface with other system but, in a client server and web development, changes to the desktop environment. Multiple application may run on the user's desktop, potentially simultaneously, so it is important to test the impact of installing new dynamic link libraries (DLLs), making operating system registry or configuration file modification, and possibly extra memory utilization.

The following were incorrect answers:

Parallel Testing This is the process of feeding test data into two systems the modified system and an alternative system and comparing the result.

Black Box Testing An integrity based form of testing associated with testing components of an information system's "functional" operating effectiveness without regards to any specific internal program structure. Applicable to integration and user acceptance testing.

Pilot Testing A preliminary test that focuses on specific and predefined aspect of a system. It is not meant to replace other testing methods, but rather to provide a limited evaluation of the system. Proof of concept are early pilot tests usually over interim platform and with only basic functionalities CISA review manual 2014 Page number 167

QUESTION 45

Which of the following is the process of feeding test data into two systems the modified system and alternative system and comparing the result?

- A. Parallel Test
- B. Black box testing
- C. Regression Testing
- D. Pilot Testing

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Parallel testing is the process of feeding test data into two systems the modified system and an alternative system and comparing the result.

For CISA exam you should know below mentioned types of testing

Alpha and Beta Testing An alpha version is early version is an early version of the application system submitted to the internal user for testing. The alpha version may not contain all the features planned for the final version. Typically, software goes to two stages testing before it consider finished. The first stage is called alpha testing is often performed only by the user within the organization developing the software. The second stage is called beta testing, a form of user acceptance testing, generally involves a limited number of external users. Beta testing is the last stage of testing, and normally involves real world exposure, sending the beta version of the product to independent beta test sites or offering it free to interested user.

Pilot Testing A preliminary test that focuses on specific and predefined aspect of a system. It is not meant to replace other testing methods, but rather to provide a limited evaluation of the system. Proof of concept are early pilot tests usually over interim platform and with only basic functionalities.

White box testing Assess the effectiveness of a software program logic. Specifically, test data are used in determining procedural accuracy or conditions of a program's specific logic path. However, testing all possible logical path in large information system is not feasible and would be cost prohibitive, and therefore is used on selective basis only.

Black Box Testing An integrity based form of testing associated with testing components of an information system's "functional" operating effectiveness without regards to any specific internal program structure.

Applicable to integration and user acceptance testing.

Function/validation testing It is similar to system testing but it is often used to test the functionality of the system against the detailed requirements to ensure that the software that has been built is traceable to customer requirements.

Regression Testing The process of rerunning a portion of a test scenario or test plan to ensure that changes or corrections have not introduced new errors. The data used in regression testing should be same as original data.

Parallel Testing This is the process of feeding test data into two systems the modified system and an alternative system and comparing the result.

Sociability Testing The purpose of these tests is to confirm that new or modified system can operate in its target environment without adversely impacting existing system. This should cover not only platform that will perform primary application processing and interface with other system but, in a client server and web development, changes to the desktop environment. Multiple application may run on the user's desktop, potentially simultaneously, so it is important to test the impact of installing new dynamic link libraries (DLLs) , making operating system registry or configuration file modification, and possibly extra memory utilization.

The following were incorrect answers:

Regression Testing The process of returning a portion of a test scenario or test plan to ensure that changes or corrections have not introduced new errors. The data used in regression testing should be same as original data.

Black Box Testing An integrity based form of testing associated with testing components of an information system's "functional" operating effectiveness without regards to any specific internal program structure.

Applicable to integration and user acceptance testing.

Pilot Testing A preliminary test that focuses on specific and predefined aspect of a system. It is not meant to replace other testing methods, but rather to provide a limited evaluation of the system. Proof of concept are early pilot tests usually over interim platform and with only basic functionalities CISA review manual 2014 Page number 167

QUESTION 46

Which of the following statement correctly describes the difference between black box testing and white box testing?

- A. Black box testing focuses on functional operative effectiveness where as white box assesses the effectiveness of software program logic
- B. White box testing focuses on functional operative effectiveness where as black box assesses the effectiveness of software program logic
- C. White box and black box testing focuses on functional operative effectiveness of an information systems without regard to any internal program structure
- D. White box and black box testing focuses on the effectiveness of the software program logic

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation For CISA exam you should know below mentioned types of testing

Alpha and Beta Testing An alpha version is early version is an early version of the application system submitted to the internal user for testing. The alpha version may not contain all the features planned for the final version. Typically, software goes to two stages testing before it consider finished. The first stage is called alpha testing is often performed only by the user within the organization developing the software. The second stage is called beta testing, a form of user acceptance testing, generally involves a limited number of external users. Beta testing is the last stage of testing, and normally involves real world exposure, sending the beta version of the product to independent beta test sites or offering it free to interested user.

Pilot Testing A preliminary test that focuses on specific and predefined aspect of a system. It is not meant to replace other testing methods, but rather to provide a limited evaluation of the system. Proof of concept are early pilot tests usually over interim platform and with only basic functionalities.

White box testing Assess the effectiveness of a software program logic. Specifically, test data are used in determining procedural accuracy or conditions of a program's specific logic path. However, testing all possible logical path in large information system is not feasible and would be cost prohibitive, and therefore is used on selective basis only.

Black Box Testing An integrity based form of testing associated with testing components of an information system's "functional" operating effectiveness without regards to any specific internal program structure.

Applicable to integration and user acceptance testing.

Function/validation testing It is similar to system testing but it is often used to test the functionality of the system against the detailed requirements to ensure that the software that has been built is traceable to customer requirements.

Regression Testing The process of rerunning a portion of a test scenario or test plan to ensure that changes or corrections have not introduced new errors. The data used in regression testing should be same as original data.

Parallel Testing This is the process of feeding test data into two systems the modified system and an alternative system and comparing the result.

Sociability Testing The purpose of these tests is to confirm that new or modified system can operate in its target environment without adversely impacting existing system. This should cover not only platform that will perform primary application processing and interface with other system but, in a client server and web development, changes to the desktop environment. Multiple application may run on the user's desktop, potentially simultaneously, so it is important to test the impact of installing new dynamic link libraries (DLLs) , making operating system registry or configuration file modification, and possibly extra memory utilization.

The following were incorrect answers:
The other options presented does not provides correct difference between black box and white box testing.
CISA review manual 2014 Page number 167

QUESTION 47

Which of the following data validation control validates input data against predefined range values?

- A. Range Check
- B. Table lookups
- C. Existence check
- D. Reasonableness check

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation In the Range Check control data should not exceed a predefined range of values

For CISA exam you should know below mentioned data validation edits and controls

Sequence Check The control number follows sequentially and any sequence or duplicated control numbers are rejected or noted on an exception report for follow-up purposes. For example, invoices are numbered sequentially. The day's invoice begins with 12001 and ends with 15045. If any invoice larger than 15045 is encountered during processing, that invoice would be rejected as an invalid invoice number.

Limit Check Data should not exceed a predefined amount. For example, payroll checks should not exceed US \$ 4000. If a check exceeds US \$ 4000, data would be rejected for further verification/authorization.

Validity Check Programmed checking of data validity in accordance with predefined criteria. For example, a payroll record contains a field for marital status and the acceptable status codes are M or S. If any other code is entered, record should be rejected.

Range Check Data should not exceed a predefined range of values. For example, product type code range from 100 to 250. Any code outside this range should be rejected as an invalid product type. **Reasonableness check** Input data are matched to predefined reasonable limits or occurrence rates. For example, a widget manufacturer usually receives an order for no more than 20 widgets. If an order for more than 20 widgets is received, the computer program should be designed to print the record with a warning indicating that the order appears unreasonable.

Table Lookups Input data comply with predefined criteria maintained in computerized table of possible values. For example, an input check enters a city code of 1 to 10. This number corresponds with a computerize table that matches a code to a city name.

Existence Check Data are entered correctly and agree with valid predefined criteria. For example, a valid transaction code must be entered in transaction code field.

Key verification The keying process is repeated by a separate individual using a machine that compares the original key stroke to the repeated keyed input. For ex. the worker number is keyed twice and compared to verify the keying process.

Check digit a numeric value that has been calculated mathematically is added to a data to ensure that original data have not been p[altered or incorrect, but Valid, value substituted. This control is effective in detecting transposition and transcription error. For ex. A check digit is added to an account number so it can be checked for accuracy when it is used.

Completeness check a filed should always contain data rather than zero or blanks. A check of each byte of that field should be performed to determine that some form of data, or not blanks or zeros, is present. For ex. A worker number on a new employee record is left blank. His is identified as a key in filed and the record would be rejected, with a request that the field be completed before the record is accepted for processing.

Duplicate check new transaction is matched to those previously input to ensure that they have not already been entered. For ex. A vendor invoice number agrees with previously recorded invoice to ensure that the current order is not a duplicate and, therefore, the vendor will not be paid twice.

Logical relationship check if a particular condition is true, then one or more additional conditions or data input relationship may be required to be true and consider the input valid. For ex. The hire data of an employee may be required to be true and consider the input valid. For ex. The hire date of an employee may be required to be more than 16 years past his her date of birth.

The following were incorrect answers:

Table Lookups Input data comply with predefined criteria maintained in computerized table of possible values. For example, an input check enters a city code of 1 to 10. This number corresponds with a computerize table that matches a code to a city name.

Existence Check Data are entered correctly and agree with valid predefined criteria. For example, a valid transaction code must be entered in transaction code field.

Reasonableness check Input data are matched to predefined reasonable limits or occurrence rates. For example, a widget manufacturer usually receives an order for no more than 20 widgets. If an order for more than 20 widgets is received, the computer program should be designed to print the record with a warning indicating that the order appears unreasonable.
CISA review manual 2014 Page number 215

QUESTION 48

Which of the following control make sure that input data comply with predefined criteria maintained in computerized table of possible values?

- A. Range Check
- B. Table lookups
- C. Existence check
- D. Reasonableness check

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation In table lookups input data comply with predefined criteria maintained in computerized table of possible values. For example, an input check enters a city code of 1 to 10. This number corresponds with a computerize table that matches a code to a city name.

For CISA exam you should know below mentioned data validation edits and controls

Sequence Check The control number follows sequentially and any sequence or duplicated control numbers are rejected or noted on an exception report for

follow-up purposes. For example, invoices are numbered sequentially. The day's invoice begins with 12001 and ends with 15045. If any invoice larger than 15045 is encountered during processing, that invoice would be rejected as an invalid invoice number.

Limit Check Data should not exceed a predefined amount. For example, payroll checks should not exceed US \$ 4000. If a check exceeds US \$ 4000, data would be rejected for further verification/authorization.

Validity Check Programmed checking of data validity in accordance with predefined criteria. For example, a payroll record contains a field for marital status and the acceptable status codes are M or S. If any other code is entered, record should be rejected.

Range Check Data should not exceed a predefined range of values. For example, product type code range from 100 to 250. Any code outside this range should be rejected as an invalid product type.

Reasonableness check Input data are matched to predefined reasonable limits or occurrence rates. For example, a widget manufacturer usually receives an order for no more than 20 widgets. If an order for more than 20 widgets is received, the computer program should be designed to print the record with a warning indicating that the order appears unreasonable.

Table Lookups Input data comply with predefined criteria maintained in computerized table of possible values. For example, an input check enters a city code of 1 to 10. This number corresponds with a computerized table that matches a code to a city name.

Existence Check Data are entered correctly and agree with valid predefined criteria. For example, a valid transaction code must be entered in transaction code field.

Key verification The keying process is repeated by a separate individual using a machine that compares the original key stroke to the repeated keyed input. For ex. the worker number is keyed twice and compared to verify the keying process.

Check digit a numeric value that has been calculated mathematically is added to a data to ensure that original data have not been altered or incorrect, but Valid, value substituted. This control is effective in detecting transposition and transcription error. For ex. A check digit is added to an account number so it can be checked for accuracy when it is used.

Completeness check a field should always contain data rather than zero or blanks. A check of each byte of that field should be performed to determine that some form of data, or not blanks or zeros, is present. For ex. A worker number on a new employee record is left blank. His is identified as a key in field and the record would be rejected, with a request that the field be completed before the record is accepted for processing. Duplicate check new transaction is matched to those previously input to ensure that they have not already been entered. For ex. A vendor invoice number agrees with previously recorded invoice to ensure that the current order is not a duplicate and, therefore, the vendor will not be paid twice.

Logical relationship check if a particular condition is true, then one or more additional conditions or data input relationship may be required to be true and consider the input valid. For ex. The hire date of an employee may be required to be true and consider the input valid. For ex. The hire date of an employee may be required to be more than 16 years past his/her date of birth.

The following were incorrect answers:

Range Check Data should not exceed a predefined range of values. For example, product type code range from 100 to 250. Any code outside this range should be rejected as an invalid product type.

Existence Check Data are entered correctly and agree with valid predefined criteria. For example, a valid transaction code must be entered in transaction code field.

Reasonableness check Input data are matched to predefined reasonable limits or occurrence rates. For example, a widget manufacturer usually receives an order for no more than 20 widgets. If an order for more than 20 widgets is received, the computer program should be designed to print the record with a warning indicating that the order appears unreasonable.

CISA review manual 2014 Page number 215

QUESTION 49

John had implemented a validation check on the marital status field of a payroll record. A payroll record contains a field for marital status and acceptable status code are M for Married or S for Single. If any other code is entered, record should be rejected. Which of the following data validation control was implemented by John?

- A. Range Check
- B. Validity Check
- C. Existence check
- D. Reasonableness check

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation In a validity check control programmed checking of data validity in accordance with predefined criteria. For example, a payroll record contains a field for marital status and the acceptable status codes are M or S. If any other code is entered, record should be rejected.

For CISA exam you should know below mentioned data validation edits and controls

Sequence Check The control number follows sequentially and any sequence or duplicated control numbers are rejected or noted on an exception report for follow-up purposes. For example, invoices are numbered sequentially. The day's invoice begins with 12001 and ends with 15045. If any invoice larger than 15045 is encountered during processing, that invoice would be rejected as an invalid invoice number.

Limit Check Data should not exceed a predefined amount. For example, payroll checks should not exceed US \$ 4000. If a check exceeds US \$ 4000, data would be rejected for further verification/authorization. **Validity Check** Programmed checking of data validity in accordance with predefined criteria. For example, a payroll record contains a field for marital status and the acceptable status codes are M or S. If any other code is entered, record should be rejected.

Range Check Data should not exceed a predefined range of values. For example, product type code range from 100 to 250. Any code outside this range should be rejected as an invalid product type.

Reasonableness check Input data are matched to predefined reasonable limits or occurrence rates. For example, a widget manufacturer usually receives an order for no more than 20 widgets. If an order for more than 20 widgets is received, the computer program should be designed to print the record with a warning indicating that the order appears unreasonable.

Table Lookups Input data comply with predefined criteria maintained in computerized table of possible values. For example, an input check enters a city code of 1 to 10. This number corresponds with a computerized table that matches a code to a city name.

Existence Check Data are entered correctly and agree with valid predefined criteria. For example, a valid transaction code must be entered in transaction code field.

Key verification The keying process is repeated by a separate individual using a machine that compares the original key stroke to the repeated keyed input. For

ex. the worker number is keyed twice and compared to verify the keying process.

Check digit a numeric value that has been calculated mathematically is added to a data to ensure that original data have not been p[altered or incorrect, but Valid, value substituted. This control is effective in detecting transposition and transcription error. For ex. A check digit is added to an account number so it can be checked for accuracy when it is used.

Completeness check a filed should always contain data rather than zero or blanks. A check of each byte of that field should be performed to determine that some form of data, or not blanks or zeros, is present. For ex. A worker number on a new employee record is left blank. His is identified as a key in filed and the record would be rejected, with a request that the field be completed before the record is accepted for processing.

Duplicate check new transaction is matched to those previously input to ensure that they have not already been entered. For ex. A vendor invoice number agrees with previously recorded invoice to ensure that the current order is not a duplicate and, therefore, the vendor will not be paid twice.

Logical relationship check if a particular condition is true, then one or more additional conditions or data input relationship may be required to be true and consider the input valid. For ex. The hire data of an employee may be required to be true and consider the input valid. For ex. The hire date of an employee may be required to be more than 16 years past his/her date of birth.

The following were incorrect answers:

Range Check -Data should not exceed a predefined range of values. For example, product type code range from 100 to 250. Any code outside this range should be rejected as an invalid product type.

Existence Check Data are entered correctly and agree with valid predefined criteria. For example, a valid transaction code must be entered in transaction code field.

Reasonableness check Input data are matched to predefined reasonable limits or occurrence rates. For example, a widget manufacturer usually receives an order for no more than 20 widgets. If an order for more than 20 widgets is received, the computer program should be designed to print the record with a warning indicating that the order appears unreasonable.
CISA review manual 2014 Page number 215

QUESTION 50

While implementing an invoice system, Lily has implemented a database control which checks that new transactions are matched to those previously input to ensure that they have not already been entered. Which of the following control is implemented by Lily?

- A. Range Check
- B. Duplicate Check
- C. Existence check
- D. Reasonableness check

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation In a duplicate check control new transaction are matched to those previously input to ensure that they have not already been entered. For ex. A vendor invoice number agrees with previously recorded invoice to ensure that the current order is not a duplicate and, therefore, the vendor will not be paid twice.

For CISA exam you should know below mentioned data validation edits and controls

Sequence Check The control number follows sequentially and any sequence or duplicated control numbers are rejected or noted on an exception report for follow-up purposes. For example, invoices are numbered sequentially. The day's invoice begins with 12001 and ends with 15045. If any invoice larger than 15045 is encountered during processing, that invoice would be rejected as an invalid invoice number.

Limit Check Data should not exceed a predefined amount. For example, payroll checks should not exceed US \$ 4000. If a check exceeds US \$ 4000, data would be rejected for further verification/authorization.

Validity Check Programmed checking of data validity in accordance with predefined criteria. For example, a payroll record contains a field for marital status and the acceptable status codes are M or S. If any other code is entered, record should be rejected.

Range Check Data should not exceed a predefined range of values. For example, product type code range from 100 to 250. Any code outside this range should be rejected as an invalid product type.

Reasonableness check Input data are matched to predefined reasonable limits or occurrence rates. For example, a widget manufacturer usually receives an order for no more than 20 widgets. If an order for more than 20 widgets is received, the computer program should be designed to print the record with a warning indicating that the order appears unreasonable.

Table Lookups Input data comply with predefined criteria maintained in computerized table of possible values. For example, an input check enters a city code of 1 to 10. This number corresponds with a computerize table that matches a code to a city name.

Existence Check Data are entered correctly and agree with valid predefined criteria. For example, a valid transaction code must be entered in transaction code field.

Key verification The keying process is repeated by a separate individual using a machine that compares the original key stroke to the repeated keyed input. For ex. the worker number is keyed twice and compared to verify the keying process.

Check digit a numeric value that has been calculated mathematically is added to a data to ensure that original data have not been p[altered or incorrect, but Valid, value substituted. This control is effective in detecting transposition and transcription error. For ex. A check digit is added to an account number so it can be checked for accuracy when it is used.

Completeness check a filed should always contain data rather than zero or blanks. A check of each byte of that field should be performed to determine that some form of data, or not blanks or zeros, is present. For ex. A worker number on a new employee record is left blank. His is identified as a key in filed and the record would be rejected, with a request that the field be completed before the record is accepted for processing.

Duplicate check new transaction is matched to those previously input to ensure that they have not already been entered. For ex. A vendor invoice number agrees with previously recorded invoice to ensure that the current order is not a duplicate and, therefore, the vendor will not be paid twice.

Logical relationship check if a particular condition is true, then one or more additional conditions or data input relationship may be required to be true and consider the input valid. For ex. The hire data of an employee may be required to be true and consider the input valid. For ex. The hire date of an employee may be required to be more than 16 years past his/her date of birth.

The following were incorrect answers:

Range Check Data should not exceed a predefined range of values. For example, product type code range from 100 to 250. Any code outside this range should be rejected as an invalid product type.

Existence Check Data are entered correctly and agree with valid predefined criteria. For example, a valid transaction code must be entered in transaction code field.

Reasonableness check Input data are matched to predefined reasonable limits or occurrence rates. For example, a widget manufacturer usually receives an order for no more than 20 widgets. If an order for more than 20 widgets is received, the computer program should be designed to print the record with a warning indicating that the order appears unreasonable.
CISA review manual 2014 Page number 215

QUESTION 51

William has been assigned a changeover task. He has to break the older system into deliverable modules. Initially, the first module of the older system is phased out using the first module of a new system. Then, the second module of the old system is phased out, using the second module of the newer system and so forth

until reaching the last module. Which of the following changeover system William needs to implement?

- A. Parallel changeover
- B. Phased changeover
- C. Abrupt changeover
- D. Pilot changeover

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation In phased changeover approach, the older system is broken into deliverables modules. Initially, the first module of older system is phased out using the first module of a new system. Then, the second module of the newer system is phased out, using the second module of the newer system and so forth until reaching the last module.
Some of the risk areas that may exist in the phased changeover area includes:

Resource challenge

Extension of the project life cycle to cover two systems.

Change management for requirements and customizations to maintain ongoing support of the older systems.

Changeover refers to an approach to shift users from using the application from the existing (old) system to the replacing (new) system.

Changeover to newer system involves four major steps or activities Conversion of files and programs; test running on test bed

Installation of new hardware, operating system, application system and the migrated data.

Training employees or user in groups

Scheduling operations and test running for go-live or changeover

Some of the risk areas related to changeover includes:

Asset safeguarding

Data integrity

System effectiveness

Change management challenges

Duplicate or missing records

The following were incorrect answers:

Parallel changeover This technique includes running the old system, then running both the old and new systems in parallel and finally full changing over to the new system after gaining confidence in the working of new system.

Abrupt changeover In the abrupt changeover approach the newer system is changed over from the older system on a cutoff date and time, and the older system is discontinued once changeover to the new system takes place.

Pilot changeover Not a valid changeover type.

CISA review manual 2014 Page number 172

QUESTION 52

In which of the following payment mode, the payer creates payment transfer instructions, signs it digitally and sends it to issuer?

- A. Electronic Money Model
- B. Electronics Checks model
- C. Electronic transfer model
- D. Electronic withdraw model

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Electronic systems are simplest of three payment models. The payer simply creates a payment transfer instructions, sign it digitally and send it to issuer. The issuer then verifies the signature on the request and performs the transfer. This type of systems requires payer to be on-line and not payee.

For CISA exam you should know below information about payment systems There are two types of parties involved in all payment systems the issuer and the user. An issuer is an entity that operates the payment service. An issuer holds the items that the payment represents. The user of the payment service performs two main functions making payments and receiving payments and therefore can be described as a payer or payee receptively.

Electronic Money Model The objective of electronic money systems is emulating physical cash. An issuer attempts to do this by creating digital certificates, which are then purchased by users who redeem them with the issuer at a later date. In the interim, certificates can be transferred among users to trade for goods or services. For the certificate to take on some of the attributes of physical cash, certain techniques are used so that when a certificate is deposited, the issuer can not determine the original withdrawer of the certificate. This provides an electronic certificate with unconditional uncertainty.

Electronic Check Model Electronic check system model real-world checks quite well and thus relatively simple to understand and implement. A users write an electronic check, which is digitally signed instruction to pay. This is transferred to another user, who then deposits the electronic check with the issuer. The issuer will verify payer's signature on the payment and transfer the fund from the payer's account to the payee's account.

Electronic Transfer Model Electronic systems are simplest of three payment models. The payer simply creates a payment transfer instructions, sign it digitally and send it to issuer. The issuer then verifies the signature on the request and performs the transfer. This type of systems requires payer to be on-line and not payee.

The following were incorrect answers:

Electronic Money Model The objective of electronic money systems is emulating physical cash. An issuer attempts to do this by creating digital certificates, which are then purchased by users who redeem them with the issuer at a later date. In the interim, certificates can be transferred among users to trade for goods or services. For the certificate to take on some of the attributes of physical cash, certain techniques are used so that when a certificate is deposited, the issuer can not determine the original withdrawer of the certificate. This provides an electronic certificate with unconditional uncertainty.

Electronic Check Model Electronic check system model real-world checks quite well and thus relatively simple to understand and implement. A users write an electronic check, which is digitally signed instruction to pay. This is transferred to another user, who then deposits the electronic check with the issuer. The issuer will verify payer's signature on the payment and transfer the fund from the payer's account to the payee's account.

Electronic Withdraw Model Not a valid type of payment system.
CISA review manual 2014 Page number 183

QUESTION 53

In which of the following payment mode, an issuer attempts to emulate physical cash by creating digital certificates, which are purchased by users who redeem them with the issuer at a later date?

- A. Electronic Money Model
- B. Electronics Checks model
- C. Electronic transfer model
- D. Electronic withdraw model

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation In an electronic money model issuer attempts to do this by creating digital certificates, which are then purchased by users who redeem them with the issuer at a later date. In the interim, certificates can be transferred among users to trade for goods or services. For the certificate to take on some of the attributes of physical cash, certain techniques are used so that when a certificate is deposited, the issuer can not determine the original withdrawer of the certificate. This provides an electronic certificate with unconditional uncertainty.

For CISA exam you should know below information about payment systems

There are two types of parties involved in all payment systems the issuer and the user. An issuer is an entity that operates the payment service. An issuer holds the items that the payment represents. The user of the payment service performs two main functions- making payments and receiving payments and therefore can be described as a payer or payee receptively.

Electronic Money Model The objective of electronic money systems is emulating physical cash. An issuer attempts to do this by creating digital certificates, which are then purchased by users who redeem them with the issuer at a later date. In the interim, certificates can be transferred among users to trade for goods or services. For the certificate to take on some of the attributes of physical cash, certain techniques are used so that when a certificate is deposited, the issuer can not determine the original withdrawer of the certificate. This provides an electronic certificate with unconditional uncertainty.

Electronic Check Model Electronic check system model real-world checks quite well and thus relatively simple to understand and implement. A users write an electronic check, which is digitally signed instruction to pay. This is transferred to another user, who then deposits the electronic check with the issuer. The issuer will verify payer's signature on the payment and transfer the fund from the payer's account to the payee's account.

Electronic Transfer Model Electronic systems are simplest of three payment models. The payer simply creates a payment transfer instructions, sign it digitally and send it to issuer. The issuer then verifies the signature on the request and performs the transfer. This type of systems requires payer to be on-line and not payee.

The following were incorrect answers:

Electronic Check Model Electronic check system model real-world checks quite well and thus relatively simple to understand and implement. A users write an electronic check, which is digitally signed instruction to pay. This is transferred to another user, who then deposits the electronic check with the issuer. The issuer will verify payer's signature on the payment and transfer the fund from the payer's account to the payee's account. **Electronic Transfer Model** -Electronic systems are simplest of three payment models. The payer simply creates a payment transfer instructions, sign it digitally and send it to issuer. The issuer then verifies the signature on the request and performs the transfer. This type of systems requires payer to be on-line and not payee.

Electronic Withdraw Model Not a valid type of payment system.
CISA review manual 2014 Page number 183

QUESTION 54

Identify the payment model from description presented below:

A users write an electronic check, which is digitally signed with instruction to pay. This is transferred to another user, who then deposits the electronic check with the issuer. The issuer will verify payer's signature on the payment and transfer the fund from the payer's account to the payee's account.

- A. Electronic Money Model
- B. Electronics Checks model
- C. Electronic transfer model
- D. Electronic withdraw model

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Electronic check system model real-world checks quite well and thus relatively simple to understand and implement. A users write an electronic check, which is digitally signed instruction to pay. This is transferred to another user, who then deposits the electronic check with the issuer. The issuer will verify payer's signature on the payment and transfer the fund from the payer's account to the payee's account.

For CISA exam you should know below information about payment systems

There are two types of parties involved in all payment systems the issuer and the user. An issuer is an entity that operates the payment service. An issuer holds the items that the payment represents. The user of the payment service performs two main functions- making payments and receiving payments and therefore can be described as a payer or payee receptively.

Electronic Money Model The objective of electronic money systems is emulating physical cash. An issuer attempts to do this by creating digital certificates, which are then purchased by users who redeem them with the issuer at a later date. In the interim, certificates can be transferred among users to trade for goods or services. For the certificate to take on some of the attributes of physical cash, certain techniques are used so that when a certificate is deposited, the issuer can not determine the original withdrawer of the certificate. This provides an electronic certificate with unconditional uncertainty.

Electronic Check Model Electronic check system model real-world checks quite well and thus relatively simple to understand and implement. A users write an electronic check, which is digitally signed instruction to pay. This is transferred to another user, who then deposits the electronic check with the issuer. The issuer

will verify payer's signature on the payment and transfer the fund from the payer's account to the payee's account.

Electronic Transfer Model Electronic systems are simplest of three payment models. The payer simply creates a payment transfer instructions, sign it digitally and send it to issuer. The issuer then verifies the signature on the request and performs the transfer. This type of systems requires payer to be on-line and not payee.

The following were incorrect answers:

Electronic Money Model The objective of electronic money systems is emulating physical cash. An issuer attempts to do this by creating digital certificates, which are then purchased by users who redeem them with the issuer at a later date. In the interim, certificates can be transferred among users to trade for goods or services. For the certificate to take on some of the attributes of physical cash, certain techniques are used so that when a certificate is deposited, the issuer can not determine the original withdrawer of the certificate. This provides an electronic certificate with unconditional uncertainty. **Electronic Transfer Model** Electronic systems are simplest of three payment models. The payer simply creates a payment transfer instructions, sign it digitally and send it to issuer. The issuer then verifies the signature on the request and performs the transfer. This type of systems requires payer to be on-line and not payee.

Electronic Withdraw Model Not a valid type of payment system.
CISA review manual 2014 Page number 183

QUESTION 55

Which of the following E-commerce model covers all the transactions between companies and government organization?

- A. B-to-C relationships
- B. B-to-B relationships
- C. B-to-E relationships
- D. B-to-G relationships

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Business-to-Government(B-to-G) relationships covers all the transactions between companies and government organizations. Currently this category is infancy, but it could expand quit rapidly as government use their own operations to promote awareness and growth of e-commerce. In addition to public procurement, administrations may also offer the option of electronic interchange for such transactions as VAT returns and the payment of corporate taxes.

For CISA exam you should know below E-commerce models:

Business-to-Consumer (B-to-C) relationships The greatest potential power of E-commerce comes from its ability to redefine relationship with customers in creating a new convenient, low-cost channel to transact business. Companies can tailor their marketing strategies to an individual customer's needs and wants. As more of its business shifts on-line, a company will have an enhanced ability to track how its customer interact with it.

Business-to-Business (B-to-B) relationships The relationship among the selling services of two or more business opens up the possibility of re-engineering business process across the boundaries that have traditionally separated external entities from each other. Because of the ease of access and the ubiquity of the Internet, for example companies can build business process that combine previously separated activities. The result is faster, higher quality and lower-cost set of transactions. The market has ever created to subdivision of B-to-B called business-to-small business(B-to-SB) relationships

Business-to-employee(B-to-E) relationships Web technologies also assist in the dissemination of information to and among an organization employees.

Business-to-Government(B-to-G) relationships covers all the transactions between companies and government organizations. Currently this category is infancy, but it could expand quit rapidly as government use their own operations to promote awareness and growth of e-commerce. In addition to public procurement,

administrations may also offer the option of electronic interchange for such transactions as VAT returns and the payment of corporate taxes.

The following were incorrect answers:

The other options presented does not covers all transactions between companies and government organizations.
CISA review manual 2014 Page number 175

QUESTION 56

Which of the following fourth generation language depends on self-contained database management systems?

- A. Query and report generator
- B. Embedded database 4GLs
- C. Relational database 4GL
- D. Application generators

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Embedded database 4GLsare depend on self-contained database management systems. These characteristics often makes them more user-friendly but also may lead to applications that are not integrated well with other product applications. Example includes FOCUS, RAMIS II and NOMAD 2.

For CISA exam you should know below mentioned types of 4GLs

Query and report generator These specialize language can extract and produce reports. Recently more powerful language has been produced that can access database records, produce complex on-line output and be developed in an almost natural language.

Embedded database 4GLs These depend on self-contained database management systems. These characteristics often makes them more user-friendly but also may lead to applications that are not integrated well with other product applications. Example includes FOCUS, RAMIS II and NOMAD 2.

Relational database 4GLs These high level language products are usually an optional feature on vendor's DBMS product line. These allow the application developer to make better use of DBMS product, but they often are not end-user-oriented. Example include SQL+ MANTIS and NATURAL.

Application generators These development tools generate lower level programming languages(3GL) such as COBOL and C. The application can be further tailored and customized. Data processing development personnel, not end user, use application generators.

The following were incorrect answers:

Query and report generator These specialize language can extract and produce reports. **Relational database 4GLs** These high level language products are usually an optional feature on vendor's DBMS product line.
Application generators These development tools generate lower level programming languages(3GL) such as COBOL and C.

QUESTION 57

Which of the following fourth generation language is a development tools to generate lower level programming languages?

- A. Query and report generator
- B. Embedded database 4GLs
- C. Relational database 4GL
- D. Application generators

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Application generators These development tools generate lower level programming languages(3GL) such as COBOL and C. The application can be further tailored and customized. Data processing development personnel, not end user, use application generators.

For CISA exam you should know below mentioned types of 4GLs

Query and report generator These specialize language can extract and produce reports. Recently more powerful language has been produced that can access database records, produce complex on-line output and be developed in an almost natural language.

Embedded database 4GLs These depend on self-contained database management systems. These characteristics often makes them more user-friendly but also may lead to applications that are not integrated well with other product applications. Example includes FOCUS, RAMIS II and NOMAD 2.

Relational database 4GLs These high level language products are usually an optional feature on vendor's DBMS product line. These allow the application developer to make better use of DBMS product, but they often are not end-user-oriented. Example include SQL+ MANTIS and NATURAL.

Application generators These development tools generate lower level programming languages(3GL) such as COBOL and C. The application can be further tailored and customized. Data processing development personnel, not end user, use application generators.

The following were incorrect answers:

Query and report generator These specialize language can extract and produce reports.

Relational database 4GLs These high level language products are usually an optional feature on vendor's DBMS product line.

Embedded database 4GLs These depend on self-contained database management systems. These characteristics often makes them more user-friendly but also may lead to applications that are not integrated well with other product applications.

CISA review manual 2014 Page number 209

QUESTION 58

Which of the following function in traditional EDI process is used for transmitting and receiving electronic documents between trading partners via dial up lines, public switched network or VAN?

- A. Communication handler
- B. EDI Interface
- C. Application System
- D. EDI Translator

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Communication handler Process for transmitting and receiving electronic documents between trading partners via dial-up lines, public switched networks, multiple dedicated lines or a value added network (VAN).

For your exam you should know below information about Traditional EDI functions.

Moving data in a batch transmission process through the traditional EDI process generally involves three functions within each trading partner's computer system

Communication handler Process for transmitting and receiving electronic documents between trading partners via dial-up lines, public switched networks, multiple dedicated lines or a value added network (VAN). VAN use computerized message switching and storage capabilities to provide electronic mailbox services similar to post offices. The VAN receives all the outbound transactions from an organization, sort them by destination and passes them to precipitants when they log on to check their mailbox and receive transmission.

EDI Interface Interface function that manipulates and routes data between the application system and the communication handler. The interface consists of two components

EDI Translator The device translates data between standard format (ANSI X12) and trading partner's propriety information.

Application Interface This interface moves electronic transactions to or from the application systems and perform data mapping. Data mapping is the process by which data are extracted from EDI translation process and integrated with the data or process of receiving company.

3. Application System The program that process the data sent to, or received from, the trading partner. Although new controls should be developed for the EDI interface, the control for existing applications, if left unchanged, are usually unaffected.

The following were incorrect answers:

EDI Interface Interface function that manipulates and routes data between the application system and the communication handler.

Application System The program that process the data sent to, or received from, the trading partner. Although new controls should be developed for the EDI interface, the control for existing applications, if left unchanged, are usually unaffected.

EDI Translator The device translates data between standard format (ANSI X12) and trading partner's propriety information.

CISA review manual 2014 Page number 178

QUESTION 59

Which of the following function in traditional EDI process manipulates and routes data between the application system and the communication handler?

- A. Communication handler
- B. EDI Interface

- C. Application System
- D. EDI Translator

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation EDI Interface manipulates and routes data between the application system and the communication handler.

For your exam you should know below information about Traditional EDI functions.

Moving data in a batch transmission process through the traditional EDI process generally involves three functions within each trading partner's computer system

Communication handler Process for transmitting and receiving electronic documents between trading partners via dial-up lines, public switched networks, multiple dedicated lines or a value added network (VAN). VAN use computerized message switching and storage capabilities to provide electronic mailbox services similar to post offices. The VAN receives all the outbound transactions from an organization, sort them by destination and passes them to precipitants when they log on to check their mailbox and receive transmission.

EDI Interface Interface function that manipulates and routes data between the application system and the communication handler. The interface consists of two components

EDI Translator The device translates data between standard format (ANSI X12) and trading partner's propriety information.

Application Interface This interface moves electronic transactions to or from the application systems and perform data mapping. Data mapping is the process by which data are extracted from EDI translation process and integrated with the data or process of receiving company.

3. **Application System** The program that process the data sent to, or received from, the trading partner. Although new controls should be developed for the EDI interface, the control for existing applications, if left unchanged, are usually unaffected.

The following were incorrect answers:

Communication handler Process for transmitting and receiving electronic documents between trading partners via dial-up lines, public switched networks, multiple dedicated lines or a value added network (VAN).

Application System The program that process the data sent to, or received from, the trading partner. Although new controls should be developed for the EDI interface, the control for existing applications, if left unchanged, are usually unaffected.

EDI Translator The device translates data between standard format (ANSI X12) and trading partner's propriety information.
CISA review manual 2014 Page number 178

QUESTION 60

Which of the following function in traditional EDI translate data between the standard format and trading partner's propriety format?

- A. Communication handler
- B. Application Interface
- C. Application System
- D. EDI Translator

Correct Answer: D
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation EDI Translator translates data between standard format (ANSI X12) and trading partner's propriety information.

For CISA Exam you should know below information about Traditional EDI functions. Moving data in a batch transmission process through the traditional EDI process generally involves three functions within each trading partner's computer system

Communication handler Process for transmitting and receiving electronic documents between trading partners via dial-up lines, public switched networks, multiple dedicated lines or a value added network (VAN). VAN use computerized message switching and storage capabilities to provide electronic mailbox services similar to post offices. The VAN receives all the outbound transactions from an organization, sort them by destination and passes them to precipitants when they log on to check their mailbox and receive transmission.

EDI Interface Interface function that manipulates and routes data between the application system and the communication handler. The interface consists of two components

EDI Translator The device translates data between standard format (ANSI X12) and trading partner's propriety information.

Application Interface This interface moves electronic transactions to or from the application systems and perform data mapping. Data mapping is the process by which data are extracted from EDI translation process and integrated with the data or process of receiving company.

3. **Application System** The program that process the data sent to, or received from, the trading partner. Although new controls should be developed for the EDI interface, the control for existing applications, if left unchanged, are usually unaffected.

The following were incorrect answers:

Communication handler Process for transmitting and receiving electronic documents between trading partners via dial-up lines, public switched networks, multiple dedicated lines or a value added network (VAN).

Application System The program that process the data sent to, or received from, the trading partner. Although new controls should be developed for the EDI interface, the control for existing applications, if left unchanged, are usually unaffected.

Application Interface This interface moves electronic transactions to or from the application systems and perform data mapping.
CISA review manual 2014 Page number 178

QUESTION 61

Which of the following component of an expert system enables the expert system to collect data from nonhuman sources, such as measurement instruments in a power plant?

- A. Decision tree
- B. Rules
- C. Semantic nets

D. Data interface

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Data Interface enables the expert system to collect data from nonhuman sources, such as measurement instruments in a power plant.

For CISA Exam you should know below information about Artificial Intelligence and Expert System Artificial intelligence is the study and application of the principles by which:

Knowledge is acquired and used
Goals are generated and achieved
Information is communicated
Collaboration is achieved
Concepts are formed
Languages are developed

Two main programming languages that have been developed for artificial intelligence are LISP and PROLOG. Expert system are compromised primary components, called shells, when they are not populated with particular data, and the shells are designed to host new expert system.

Keys to the system is the knowledge base (KB), which contains specific information or fact patterns associated with a particular subject matter and the rule for interpreting these facts. The KB interface with a database in obtaining data to analyze a particular problem in deriving an expert conclusion. The information in the KB can be expressed in several ways:

Decision Tree Using questionnaires to lead the user through a series of choices, until a conclusion is reached. Flexibility is compromised because the user must answer the questions in an exact sequence.

Rule Expressing declarative knowledge through the use of if-then relationships. For example, if a patient's body temperature is over 39 degrees Celsius and their pulse is under 60, then they might be suffering from a certain disease.

Semantic nets Consist of a graph in which the node represent physical or conceptual object and the arcs describe the relationship between the nodes. Semantic nets resemble a data flow diagram and make use of an inheritance mechanism to prevent duplication of a data.

Additionally, the inference engine shown is a program that uses the KB and determines the most appropriate outcome based on the information supplied by the user. In addition, an expert system includes the following components

Knowledge interface Allows the expert to enter knowledge into the system without the traditional mediation of a software engineer.

Data Interface Enables the expert system to collect data from nonhuman sources, such as measurement instruments in a power plant.

The following were incorrect answers:

Decision Tree Using questionnaires to lead the user through a series of choices, until a conclusion is reached. Flexibility is compromised because the user must answer the questions in an exact sequence.

Rule - Expressing declarative knowledge through the use of if-then relationships.

Semantic nets - Semantic nets consist of a graph in which the node represent physical or conceptual object and the arcs describe the relationship between the nodes.

CISA review manual 2014 Page number 187

QUESTION 62

Which of the following component of an expert system allows the expert to enter knowledge into the system without the traditional mediation of a software engineer?

- A. Decision tree
- B. Rules
- C. Semantic nets
- D. Knowledge interface

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Knowledge interface allows the expert to enter knowledge into the system without the traditional mediation of a software engineer.

For CISA Exam you should know below information about Artificial Intelligence and Expert System Artificial intelligence is the study and application of the principles by which:

Knowledge is acquired and used
Goals are generated and achieved
Information is communicated
Collaboration is achieved
Concepts are formed
Languages are developed

Two main programming languages that have been developed for artificial intelligence are LISP and PROLOG. Expert system are compromised primary components, called shells, when they are not populated with particular data, and the shells are designed to host new expert system.

Keys to the system is the knowledge base (KB), which contains specific information or fact patterns associated with a particular subject matter and the rule for interpreting these facts. The KB interface with a database in obtaining data to analyze a particular problem in deriving an expert conclusion. The information in the KB can be expressed in several ways:

Decision Tree Using questionnaires to lead the user through a series of choices, until a conclusion is reached. Flexibility is compromised because the user must answer the questions in an exact sequence.

Rule Expressing declarative knowledge through the use of if-then relationships. For example, if a patient's body temperature is over 39 degrees Celsius and their pulse is under 60, then they might be suffering from a certain disease.

Semantic nets Consist of a graph in which the node represent physical or conceptual object and the arcs describe the relationship between the nodes. Semantic nets resemble a data flow diagram and make use of an inheritance mechanism to prevent duplication of a data.

Additionally, the inference engine shown is a program that uses the KB and determines the most appropriate outcome based on the information supplied by the user. In addition, an expert system includes the following components

Knowledge interface Allows the expert to enter knowledge into the system without the traditional mediation of a software engineer.

Data Interface Enables the expert system to collect data from nonhuman sources, such as measurement instruments in a power plant.

The following were incorrect answers:

Decision Tree Using questionnaires to lead the user through a series of choices, until a conclusion is reached. Flexibility is compromised because the user must answer the questions in an exact sequence. **Rule** - Expressing declarative knowledge through the use of if-then relationships.

Semantic nets Semantic nets consist of a graph in which the node represent physical or conceptual object and the arcs describe the relationship between the nodes.

CISA review manual 2014 Page number 187

QUESTION 63

Which of the following method of expressing knowledge base consist of a graph in which nodes represent physical or conceptual objects and the arcs describes the relationship between nodes?

- A. Decision tree
- B. Rules
- C. Semantic nets
- D. Knowledge interface

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Semantic nets consist of a graph in which the node represent physical or conceptual object and the arcs describe the relationship between the nodes.

For CISA Exam you should know below information about Artificial Intelligence and Expert System Artificial intelligence is the study and application of the principles by which:

Knowledge is acquired and used
Goals are generated and achieved
Information is communicated
Collaboration is achieved
Concepts are formed

Languages are developed

Two main programming languages that have been developed for artificial intelligence are LISP and PROLOG. Expert system are compromised primary components, called shells, when they are not populated with particular data, and the shells are designed to host new expert system.

Keys to the system is the knowledge base (KB), which contains specific information or fact patterns associated with a particular subject matter and the rule for interpreting these facts. The KB interface with a database in obtaining data to analyze a particular problem in deriving an expert conclusion. The information in the KB can be expressed in several ways:

Decision Tree Using questionnaires to lead the user through a series of choices, until a conclusion is reached. Flexibility is compromised because the user must answer the questions in an exact sequence.

Rule Expressing declarative knowledge through the use of if-then relationships. For example, if a patient's body temperature is over 39 degrees Celsius and their pulse is under 60, then they might be suffering from a certain disease.

Semantic nets Consist of a graph in which the node represent physical or conceptual object and the arcs describe the relationship between the nodes. Semantic nets resemble a data flow diagram and make use of an inheritance mechanism to prevent duplication of a data. Additionally, the inference engine shown is a program that uses the KB and determines the most appropriate outcome based on the information supplied by the user. In addition, an expert system includes the following components

Knowledge interface Allows the expert to enter knowledge into the system without the traditional mediation of a software engineer.

Data Interface Enables the expert system to collect data from nonhuman sources, such as measurement instruments in a power plant.

The following were incorrect answers:

Decision Tree Using questionnaires to lead the user through a series of choices, until a conclusion is reached. Flexibility is compromised because the user must answer the questions in an exact sequence.

Rule Expressing declarative knowledge through the use of if-then relationships.

Semantic nets - Semantic nets consist of a graph in which the node represent physical or conceptual object and the arcs describe the relationship between the nodes.

CISA review manual 2014 Page number 187

QUESTION 64

The information in the knowledge base can be expressed in several ways. Which of the following way uses questionnaires to lead the user through a series of choices until a conclusion is reached?

- A. Decision tree
- B. Rules
- C. Semantic nets
- D. Knowledge interface

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Decision tree uses questionnaires to lead the user through a series of choices, until a conclusion is reached. Flexibility is compromised because the user must answer the questions in an exact sequence.

For CISA Exam you should know below information about Artificial Intelligence and Expert System Artificial intelligence is the study and application of the principles by which:

Knowledge is acquired and used
Goals are generated and achieved
Information is communicated
Collaboration is achieved
Concepts are formed
Languages are developed

Two main programming languages that have been developed for artificial intelligence are LISP and PROLOG. Expert system are compromised primary components, called shells, when they are not populated with particular data, and the shells are designed to host new expert system.

Keys to the system is the knowledge base (KB), which contains specific information or fact patterns associated with a particular subject matter and the rule for interpreting these facts. The KB interface with a database in obtaining data to analyze a particular problem in deriving an expert conclusion. The information in the KB can be expressed in several ways:

Decision Tree Using questionnaires to lead the user through a series of choices, until a conclusion is reached. Flexibility is compromised because the user must answer the questions in an exact sequence.

Rule Expressing declarative knowledge through the use of if-then relationships. For example, if a patient's body temperature is over 39 degrees Celsius and their pulse is under 60, then they might be suffering from a certain disease.

Semantic nets Consist of a graph in which the node represent physical or conceptual object and the arcs describe the relationship between the nodes. Semantic nets resemble a data flow diagram and make use of an inheritance mechanism to prevent duplication of a data.

Additionally, the inference engine shown is a program that uses the KB and determines the most appropriate outcome based on the information supplied by the user. In addition, an expert system includes the following components

Knowledge interface Allows the expert to enter knowledge into the system without the traditional mediation of a software engineer.

Data Interface Enables the expert system to collect data from nonhuman sources, such as measurement instruments in a power plant.

The following were incorrect answers:

Rule Expressing declarative knowledge through the use of if-then relationships.

Semantic nets Semantic nets consist of a graph in which the node represent physical or conceptual object and the arcs describe the relationship between the nodes.

Knowledge interface Allows the expert to enter knowledge into the system without the traditional mediation of a software engineer.

CISA review manual 2014 Page number 187

QUESTION 65

An IS auditor should aware of various analysis models used by data architecture. Which of the following analysis model depict data entities and how they relate?

- A. Context Diagrams
- B. Activity Diagrams
- C. Swim-lane diagrams
- D. Entity relationship diagrams

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Entity relationship diagram Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance.

To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)

A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data Source Layer Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A property constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum

sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability to generate repeat business with existing customers.

Data Mart Layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concern with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Context diagram Outline the major processes of an organization and the external parties with which business interacts.

Activity or swim-lane diagram De-construct business processes.

Entity relationship diagram Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Context diagram Outline the major processes of an organization and the external parties with which business interacts.

Activity or swim-lane diagram De-construct business processes.

CISA review manual 2014 Page number 188

QUESTION 66

An IS auditor should aware of various analysis models used by data architecture. Which of the following analysis model outline the major process of an organization and the external parties with which business interacts?

- A. Context Diagrams
- B. Activity Diagrams
- C. Swim-lane diagrams
- D. Entity relationship diagrams

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Context diagram Outline the major processes of an organization and the external parties with which business interacts.

For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance.

To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)

A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data Source Layer Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A property constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability to generate repeat business with existing customers.

Data Mart Layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concerned with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Activity or swim-lane diagram De-construct business processes.

Entity relationship diagram Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Context diagram Outline the major processes of an organization and the external parties with which business interacts.

Activity or swim-lane diagram De-construct business processes.
CISA review manual 2014 Page number 188

QUESTION 67

Which of the following layer of an enterprise data flow architecture is concerned with basic data communication?

- A. Data preparation layer
- B. Desktop Access Layer
- C. Internet/Intranet layer
- D. Data access layer

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.
For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance.

To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)

A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced score cards and digital dashboards.

Data Source Layer Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A properly constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the

company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability to generate repeat business with existing customers.

Data Mart Layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concerned with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Activity or swim-lane diagram De-construct business processes.

Entity relationship diagram Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Desktop access layer or presentation layer is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced score cards and digital dashboards.

Data preparation layer This layer is concerned with the assembly and preparation of data for loading into

data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed.

Data access layer this layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.
CISA review manual 2014 Page number 188

QUESTION 68

Which of the following layer of an enterprise data flow architecture is concerned with transporting information between the various layers?

- A. Data preparation layer
- B. Desktop Access Layer
- C. Application messaging layer
- D. Data access layer

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Application messaging layer This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.
For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance.

To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)

A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced score cards and digital dashboards.

Data Source Layer Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A property constituted

DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability to generate repeat business with existing customers.

Data Mart Layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concerned with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Activity or swim-lane diagram De-construct business processes.

Entity relationship diagram Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Desktop access layer or presentation layer is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed.

Data access layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database. CISA review manual 2014 Page number 188

QUESTION 69

Which of the following layer of an enterprise data flow architecture does the scheduling of the tasks necessary to build and maintain the Data Warehouse (DW) and also populates Data Marts?

- A. Data preparation layer
- B. Desktop Access Layer
- C. Warehouse management layer
- D. Data access layer

Correct Answer: C
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation **Warehouse Management Layer** The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security. For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance. To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)
A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data Source Layer Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A properly constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability to generate repeat business with existing customers.

Data Mart Layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business

line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concerned with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Activity or swim-lane diagram De-construct business processes.

Entity relationship diagram Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable

business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Desktop access layer or presentation layer is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced score cards and digital dashboards.

Data preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed.

Data access layer this layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database. CISA review manual 2014 Page number 188

QUESTION 70

Which of the following layer of an enterprise data flow architecture represents subset of information from the core Data Warehouse selected and organized to meet the needs of a particular business unit or business line?

- A. Data preparation layer
- B. Desktop Access Layer
- C. Data Mart layer
- D. Data access layer

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation **Data Mart layer** Data mart represents subset of information from the core Data Warehouse selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure. For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance. To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)
A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced score cards and digital dashboards.

Data Source Layer Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A properly constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability to generate repeat business with existing customers.

Data Mart Layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concern with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Activity or swim-lane diagram De-construct business processes. **Entity relationship diagram** Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Desktop access layer or presentation layer is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed.

Data access layer his layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database. CISA review manual 2014 Page number 188

QUESTION 71

Which of the following layer of an enterprise data flow architecture is concerned with the assembly and preparation of data for loading into data marts?

- A. Data preparation layer
- B. Desktop Access Layer
- C. Data Mart layer
- D. Data access layer

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation **Data preparation layer** This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance. To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)

A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data Source Layer Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A property constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability to generate repeat business with existing customers.

Data Mart Layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business

line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concern with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication

of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Activity or swim-lane diagram De-construct business processes. **Entity relationship diagram** Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Desktop access layer or presentation layer is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data Mart layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data access layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database. CISA review manual 2014 Page number 188

QUESTION 72

Which of the following layer of an enterprise data flow architecture is responsible for data copying, transformation in Data Warehouse (DW) format and quality control?

- A. Data Staging and quality layer
- B. Desktop Access Layer
- C. Data Mart layer
- D. Data access layer

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation **Data Staging and quality layer** This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers. For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance. To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)
A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data Source Layer Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.
External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.
Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A properly constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability

to generate repeat business with existing customers.

Data Mart Layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concerned with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Activity or swim-lane diagram De-construct business processes. **Entity relationship diagram** Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Desktop access layer or presentation layer is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced score cards and digital dashboards.

Data Mart layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data access layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database. CISA review manual 2014 Page number 188

QUESTION 73

Which of the following layer of an enterprise data flow architecture represents subsets of information from the core data warehouse?

- A. Presentation layer
- B. Desktop Access Layer
- C. Data Mart layer
- D. Data access layer

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation **Data Mart layer** Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some

form on-line analytical processing (OLAP) data structure.

For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance. To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)

A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced score cards and digital dashboards.

Data Source Layer Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A properly constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability

to generate repeat business with existing customers.

Data Mart Layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concern with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and

complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Activity or swim-lane diagram De-construct business processes.

Entity relationship diagram Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Desktop access layer or presentation layer is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data access layer his layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database. CISA review manual 2014 Page number 188

QUESTION 74

Which of the following layer from an enterprise data flow architecture captures all data of interest to an organization and organize it to assist in reporting and analysis?

- A. Desktop access layer
- B. Data preparation layer
- C. Core data warehouse
- D. Data access layer

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Core data warehouse This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A properly constituted DW should support three basic form of an inquiry.

For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance.

To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)

A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data Source Layer Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A properly constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability

to generate repeat business with existing customers.

Data Mart Layer Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer This layer is concerned with the assembly and preparation of data for loading into

data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concerned with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:
Activity or swim-lane diagram De-construct business processes.

Entity relationship diagram Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Desktop access layer or presentation layer is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced score cards and digital dashboards.

Data access layer this layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database. Data preparation layer -This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed.
CISA review manual 2014 Page number 188

QUESTION 75

Which of the following layer in an enterprise data flow architecture derives enterprise information from operational data, external data and nonoperational data?

- A. Data preparation layer
- B. Data source layer
- C. Data mart layer
- D. Data access layer

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance. To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components
The enterprise data flow architecture (EDFA)
A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced score cards and digital dashboards.

Data Source Layer - Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse -This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A properly constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability to generate repeat business with existing customers.

Data Mart Layer- Data mart represents subset of information from the core DW selected and organized to

meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer -This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer -This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer -This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concern with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer - Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer -The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer -This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Activity or swim-lane diagram De-construct business processes.

Entity relationship diagram -Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Data mart layer - Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data access layer - his layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database. **Data preparation layer** -This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed.

CISA review manual 2014 Page number 188

QUESTION 76

Which of the following layer in an enterprise data flow architecture is directly death with by end user with information?

- A. Desktop access layer
- B. Data preparation layer
- C. Data mart layer
- D. Data access layer

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Presentation/desktop access layer is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards. For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance.

To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)

A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data Source Layer - Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse -This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A property constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability to generate repeat business with existing customers.

Data Mart Layer- Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer -This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer -This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer -This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concern with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer -Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer -The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer -This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Activity or swim-lane diagram De-construct business processes.

Entity relationship diagram -Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Data mart layer - Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data access layer - his layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database. Data preparation layer -This layer is concerned with the assembly and preparation of data for loading into data

marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed.
CISA review manual 2014 Page number 188

QUESTION 77

Which of the following property of the core date warehouse layer of an enterprise data flow architecture uses common attributes to access a cross section of an information in the warehouse?

- A. Drill up
- B. Drill down
- C. Drill across
- D. Historical Analysis

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

For CISA exam you should know below information about business intelligence:

Business intelligence(BI) is a broad field of IT encompasses the collection and analysis of information to assist decision making and assess organizational performance.

To deliver effective BI, organizations need to design and implement a data architecture. The complete data architecture consists of two components

The enterprise data flow architecture (EDFA)
A logical data architecture

Various layers/components of this data flow architecture are as follows:

Presentation/desktop access layer This is where end users directly deal with information. This layer includes familiar desktop tools such as spreadsheets, direct querying tools, reporting and analysis suits offered by vendors such as Congas and business objects, and purpose built application such as balanced source cards and digital dashboards.

Data Source Layer - Enterprise information derives from number of sources:

Operational data Data captured and maintained by an organization's existing systems, and usually held in system-specific database or flat files.

External Data Data provided to an organization by external sources. This could include data such as customer demographic and market share information.

Nonoperational data Information needed by end user that is not currently maintained in a computer accessible format.

Core data warehouse -This is where all the data of interest to an organization is captured and organized to assist reporting and analysis. DWs are normally instituted as large relational databases. A property constituted DW should support three basic form of an inquiry.

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate

data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used to refine the analysis.

Drill across Use common attributes to access a cross section of information in the warehouse such as sum sales across all product lines by customer and group of customers according to length of association with the company.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability to generate repeat business with existing customers.

Data Mart Layer- Data mart represents subset of information from the core DW selected and organized to meet the needs of a particular business unit or business line. Data mart can be relational databases or some form on-line analytical processing (OLAP) data structure.

Data Staging and quality layer -This layer is responsible for data copying, transformation into DW format and quality control. It is particularly important that only reliable data into core DW. This layer needs to be able to deal with problems periodically thrown by operational systems such as change to account number format and reuse of old accounts and customer numbers.

Data Access Layer -This layer operates to connect the data storage and quality layer with data stores in the data source layer and, in the process, avoiding the need to know to know exactly how these data stores are organized. Technology now permits SQL access to data even if it is not stored in a relational database.

Data Preparation layer -This layer is concerned with the assembly and preparation of data for loading into data marts. The usual practice is to pre-calculate the values that are loaded into OLAP data repositories to increase access speed. Data mining is concern with exploring large volume of data to determine patterns and trends of information. Data mining often identifies patterns that are counterintuitive due to number and complexity of data relationships. Data quality needs to be very high to not corrupt the result.

Metadata repository layer - Metadata are data about data. The information held in metadata layer needs to extend beyond data structure names and formats to provide detail on business purpose and context. The metadata layer should be comprehensive in scope, covering data as they flow between the various layers, including documenting transformation and validation rules.

Warehouse Management Layer -The function of this layer is the scheduling of the tasks necessary to build and maintain the DW and populate data marts. This layer is also involved in administration of security.

Application messaging layer -This layer is concerned with transporting information between the various layers. In addition to business data, this layer encompasses generation, storage and targeted communication of control messages.

Internet/Intranet layer This layer is concerned with basic data communication. Included here are browser based user interface and TCP/IP networking.

Various analysis models used by data architects/ analysis follows:

Activity or swim-lane diagram De-construct business processes.

Entity relationship diagram -Depict data entities and how they relate. These data analysis methods obviously play an important part in developing an enterprise data model. However, it is also crucial that knowledgeable business operative is involved in the process. This way proper understanding can be obtained of the business purpose and context of the data. This also mitigates the risk of replication of suboptimal data configuration from existing systems and database into DW.

The following were incorrect answers:

Drilling up and drilling down Using dimension of interest to the business, it should be possible to aggregate data as well as drill down. Attributes available at the more granular levels of the warehouse can also be used

to refine the analysis.

Historical Analysis The warehouse should support this by holding historical, time variant data. An example of historical analysis would be to report monthly store sales and then repeat the analysis using only customer who were preexisting at the start of the year in order to separate the effective new customer from the ability to generate repeat business with existing customers.

CISA review manual 2014 Page number 188

QUESTION 78

Which of the following level in CMMI model focuses on process innovation and continuous optimization?

- A. Level 4
- B. Level 5
- C. Level 3
- D. Level 2

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Level 5 is the optimizing process and focus on process innovation and continuous integration.

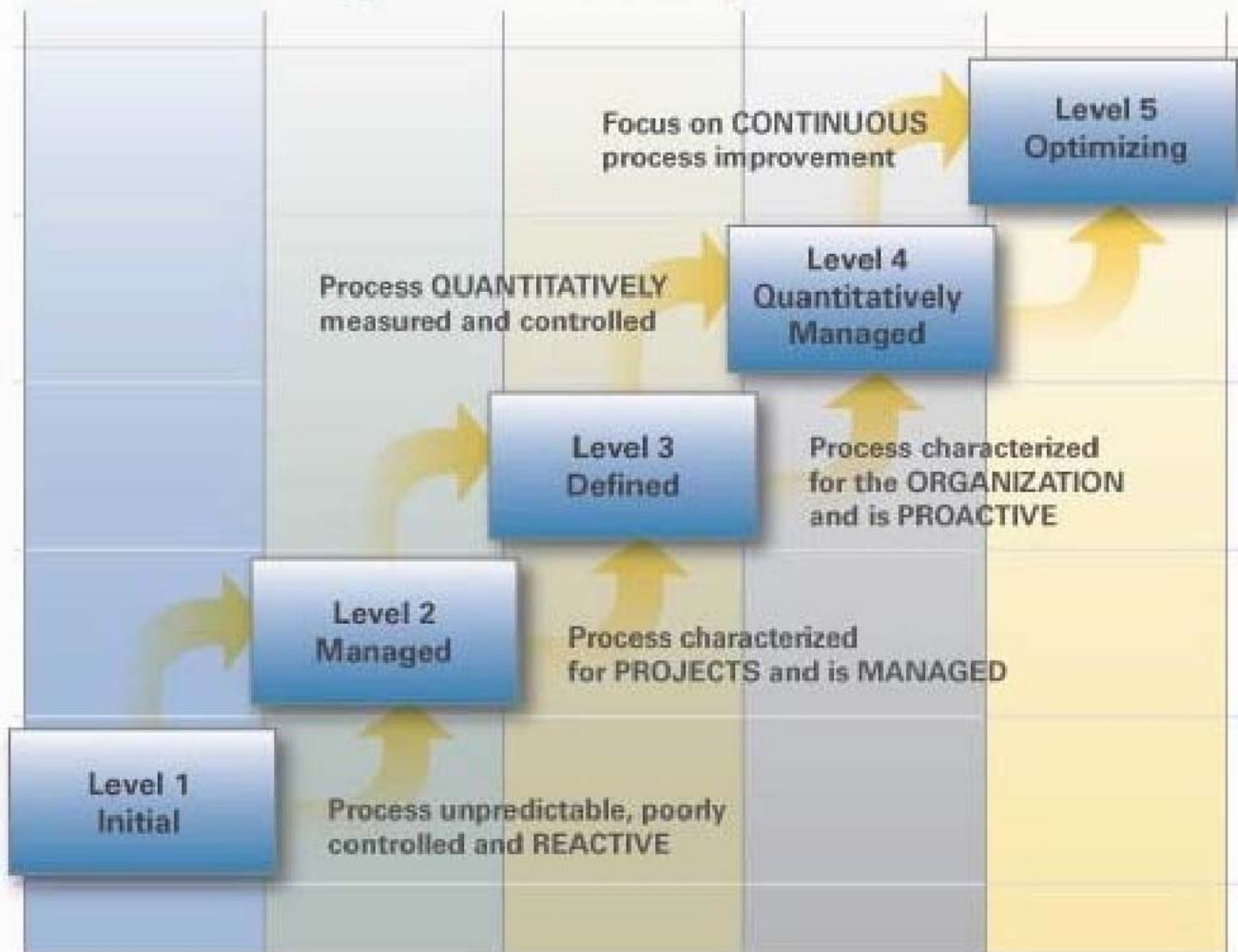
For CISA Exam you should know below information about Capability Maturity Model Integration (CMMI) mode:

Maturity model

A maturity model can be viewed as a set of structured levels that describe how well the behaviors, practices and processes of an organization can reliably and sustainably produce required outcomes.

CMMI Levels

CMMI Staged Maturity Levels



A maturity model can be used as a benchmark for comparison and as an aid to understanding - for example, for comparative assessment of different organizations where there is something in common that can be used as a basis for comparison. In the case of the CMM, for example, the basis for comparison would be the organizations' software development processes.

Structure

The model involves five aspects:

Maturity Levels: a 5-level process maturity continuum - where the uppermost (5th) level is a notional ideal state where processes would be systematically managed by a combination of process optimization and continuous process improvement.

Key Process Areas: a Key Process Area identifies a cluster of related activities that, when performed together, achieve a set of goals considered important.

Goals: the goals of a key process area summarize the states that must exist for that key process area to have been implemented in an effective and lasting way. The extent to which the goals have been accomplished is an indicator of how much capability the organization has established at that maturity level. The goals signify the scope, boundaries, and intent of each key process area.

Common Features: common features include practices that implement and institutionalize a key process area. There are five types of common features: commitment to perform, ability to perform, activities performed, measurement and analysis, and verifying implementation.

Key Practices: The key practices describe the elements of infrastructure and practice that contribute most effectively to the implementation and institutionalization of the area.

Levels

There are five levels defined along the continuum of the model and, according to the SEI: "Predictability, effectiveness, and control of an organization's software processes are believed to improve as the organization moves up these five levels. While not rigorous, the empirical evidence to date supports this belief".[citation needed]

Initial (chaotic, ad hoc, individual heroics) - the starting point for use of a new or undocumented repeat process.

Repeatable - the process is at least documented sufficiently such that repeating the same steps may be attempted.

Defined - the process is defined/confirmed as a standard business process, and decomposed to levels 0, 1 and 2 (the last being Work Instructions).

Managed - the process is quantitatively managed in accordance with agreed-upon metrics. **Optimizing** - process management includes deliberate process optimization/improvement.

Within each of these maturity levels are Key Process Areas which characteristic that level, and for each such area there are five factors: goals, commitment, ability, measurement, and verification. These are not necessarily unique to CMM, representing -- as they do -- the stages that organizations must go through on the way to becoming mature.

The model provides a theoretical continuum along which process maturity can be developed incrementally from one level to the next. Skipping levels is not allowed/feasible.

Level 1 - Initial (Chaotic)

It is characteristic of processes at this level that they are (typically) undocumented and in a state of dynamic

change, tending to be driven in an ad hoc, uncontrolled and reactive manner by users or events. This provides a chaotic or unstable environment for the processes.

Level 2 - Repeatable

It is characteristic of processes at this level that some processes are repeatable, possibly with consistent results. Process discipline is unlikely to be rigorous, but where it exists it may help to ensure that existing processes are maintained during times of stress.

Level 3 - Defined

It is characteristic of processes at this level that there are sets of defined and documented standard processes established and subject to some degree of improvement over time. These standard processes are in place (i.e., they are the AS-IS processes) and used to establish consistency of process performance across the organization.

Level 4 - Managed

It is characteristic of processes at this level that, using process metrics, management can effectively control the AS-IS process (e.g., for software development). In particular, management can identify ways to adjust and adapt the process to particular projects without measurable losses of quality or deviations from specifications.

Process Capability is established from this level.

Level 5 - Optimizing

It is a characteristic of processes at this level that the focus is on continually improving process performance through both incremental and innovative technological changes/improvements.

At maturity level 5, processes are concerned with addressing statistical common causes of process variation and changing the process (for example, to shift the mean of the process performance) to improve process performance. This would be done at the same time as maintaining the likelihood of achieving the established quantitative process-improvement objectives.

The following were incorrect answers:

Level 4 Focus on process management and process control

Level 3 Process definition and process deployment.

Level 2 Performance management and work product management.

CISA review manual 2014 Page number 188

QUESTION 79

Which of the following level in CMMI model focuses on process definition and process deployment?

- A. Level 4
- B. Level 5
- C. Level 3
- D. Level 2

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Level 3 is the defined step and focus on process definition and process deployment.

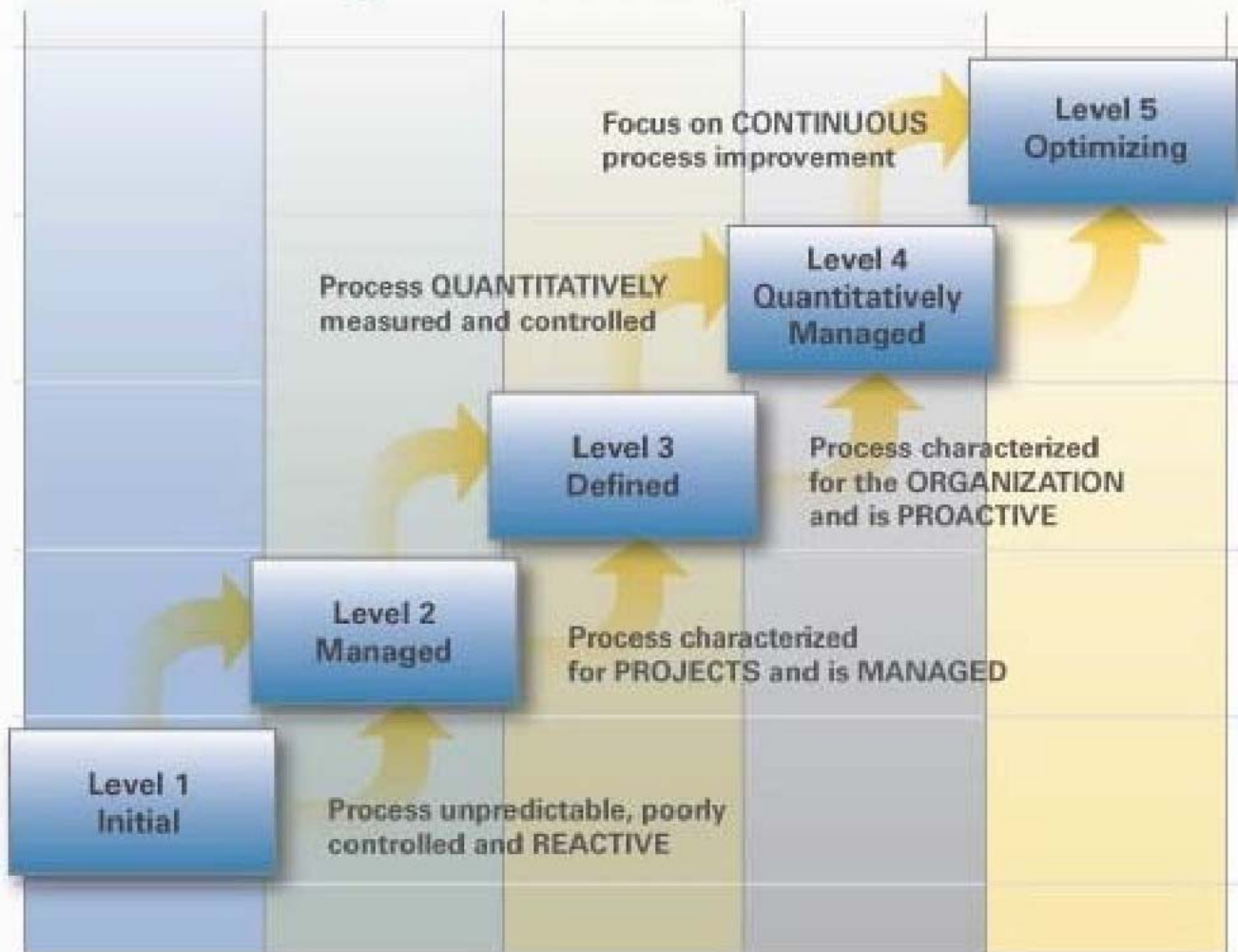
For CISA Exam you should know below information about Capability Maturity Model Integration (CMMI) mode:

Maturity model

A maturity model can be viewed as a set of structured levels that describe how well the behaviors, practices and processes of an organization can reliably and sustainably produce required outcomes.

CMMI Levels

CMMI Staged Maturity Levels



A maturity model can be used as a benchmark for comparison and as an aid to understanding - for example, for comparative assessment of different organizations where there is something in common that can be used as a basis for comparison. In the case of the CMM, for example, the basis for comparison would be the organizations' software development processes.
Structure

The model involves five aspects:

Maturity Levels: a 5-level process maturity continuum - where the uppermost (5th) level is a notional ideal state where processes would be systematically managed by a combination of process optimization and continuous process improvement.

Key Process Areas: a Key Process Area identifies a cluster of related activities that, when performed together, achieve a set of goals considered important.

Goals: the goals of a key process area summarize the states that must exist for that key process area to have been implemented in an effective and lasting way. The extent to which the goals have been accomplished is an indicator of how much capability the organization has established at that maturity level. The goals signify the scope, boundaries, and intent of each key process area.

Common Features: common features include practices that implement and institutionalize a key process area. There are five types of common features: commitment to perform, ability to perform, activities performed, measurement and analysis, and verifying implementation.

Key Practices: The key practices describe the elements of infrastructure and practice that contribute most effectively to the implementation and institutionalization of the area.

Levels

There are five levels defined along the continuum of the model and, according to the SEI: "Predictability, effectiveness, and control of an organization's software processes are believed to improve as the organization moves up these five levels. While not rigorous, the empirical evidence to date supports this belief".[citation needed]

Initial (chaotic, ad hoc, individual heroics) - the starting point for use of a new or undocumented repeat process.

Repeatable - the process is at least documented sufficiently such that repeating the same steps may be attempted.

Defined - the process is defined/confirmed as a standard business process, and decomposed to levels 0, 1 and 2 (the last being Work Instructions).

Managed - the process is quantitatively managed in accordance with agreed-upon metrics. **Optimizing** - process management includes deliberate process optimization/improvement.

Within each of these maturity levels are Key Process Areas which characteristic that level, and for each such area there are five factors: goals, commitment, ability, measurement, and verification. These are not necessarily unique to CMM, representing -- as they do -- the stages that organizations must go through on the way to becoming mature.

The model provides a theoretical continuum along which process maturity can be developed incrementally from one level to the next. Skipping levels is not allowed/feasible.

Level 1 - Initial (Chaotic)

It is characteristic of processes at this level that they are (typically) undocumented and in a state of dynamic change, tending to be driven in an ad hoc, uncontrolled and reactive manner by users or events. This provides a chaotic or unstable environment for the processes.

Level 2 - Repeatable

It is characteristic of processes at this level that some processes are repeatable, possibly with consistent results. Process discipline is unlikely to be rigorous, but where it exists it may help to ensure that existing processes are maintained during times of stress.

Level 3 - Defined

It is characteristic of processes at this level that there are sets of defined and documented standard processes established and subject to some degree of improvement over time. These standard processes are in place (i.e., they are the AS-IS processes) and used to establish consistency of process performance across the organization.

Level 4 - Managed

It is characteristic of processes at this level that, using process metrics, management can effectively control the AS-IS process (e.g., for software development). In particular, management can identify ways to adjust and

adapt the process to particular projects without measurable losses of quality or deviations from specifications. Process Capability is established from this level.

Level 5 - Optimizing

It is a characteristic of processes at this level that the focus is on continually improving process performance through both incremental and innovative technological changes/improvements.

At maturity level 5, processes are concerned with addressing statistical common causes of process variation and changing the process (for example, to shift the mean of the process performance) to improve process performance. This would be done at the same time as maintaining the likelihood of achieving the established quantitative process-improvement objectives.

The following were incorrect answers:

Level 4 Focus on process management and process control

Level 5 Process innovation and continuous optimization.

Level 2 Performance management and work product management.

CISA review manual 2014 Page number 188

QUESTION 80

ISO 9126 is a standard to assist in evaluating the quality of a product. Which of the following is defined as a set of attributes that bear on the existence of a set of functions and their specified properties?

- A. Reliability
- B. Usability
- C. Functionality
- D. Maintainability

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Functionality - A set of attributes that bear on the existence of a set of functions and their specified properties.

The functions are those that satisfy stated or implied needs.

Suitability

Accuracy

Interoperability

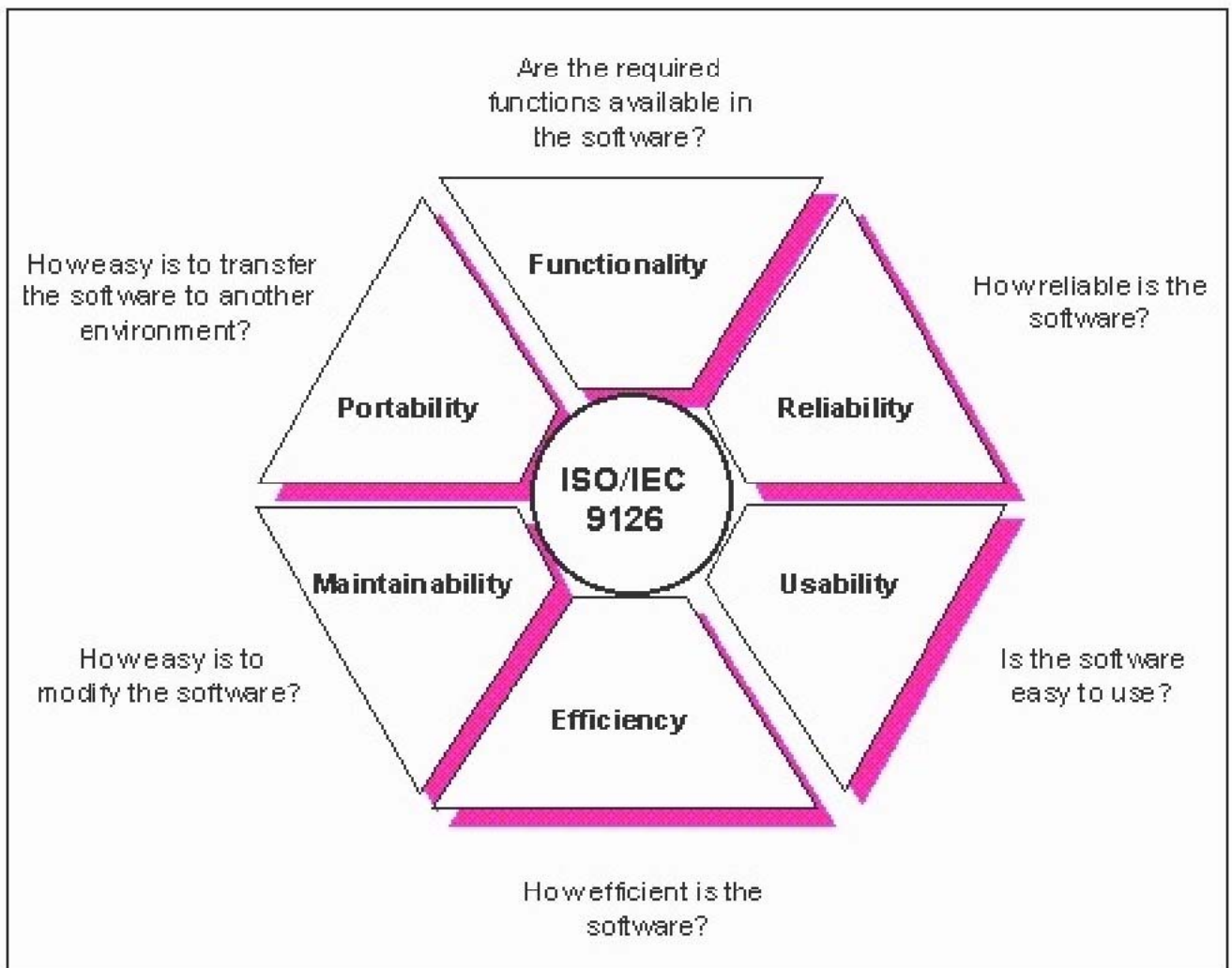
Security

Functionality Compliance

For CISA Exam you should know below information about ISO 9126 model:

ISO/IEC 9126 Software engineering -- Product quality was an international standard for the evaluation of software quality. It has been replaced by ISO/IEC 25010:2011.[1] The fundamental objective of the ISO/IEC 9126 standard is to address some of the well-known human biases that can adversely affect the delivery and perception of a software development project. These biases include changing priorities after the start of a project or not having any clear definitions of "success." By clarifying, then agreeing on the project priorities and subsequently converting abstract priorities (compliance) to measurable values (output data can be validated against schema X with zero intervention), ISO/IEC 9126 tries to develop a common understanding of the project's objectives and goals.

ISO 9126



The standard is divided into four parts:

Quality model
 External metrics
 Internal metrics
 Quality in use metrics.

Quality Model

The quality model presented in the first part of the standard, ISO/IEC 9126-1,[2] classifies software quality in a structured set of characteristics and sub-characteristics as follows:

Functionality - A set of attributes that bear on the existence of a set of functions and their specified properties. The functions are those that satisfy stated or implied needs.

Suitability
 Accuracy
 Interoperability
 Security
 Functionality Compliance

Reliability - A set of attributes that bear on the capability of software to maintain its level of performance under stated conditions for a stated period of time.

Maturity
 Fault Tolerance
 Recoverability
 Reliability Compliance

Usability - A set of attributes that bear on the effort needed for use, and on the individual assessment of such use, by a stated or implied set of users.

Understandability
 Learn ability
 Operability
 Attractiveness
 Usability Compliance

Efficiency - A set of attributes that bear on the relationship between the level of performance of the software and the amount of resources used, under stated conditions.

Time Behavior
 Resource Utilization
 Efficiency Compliance

Maintainability - A set of attributes that bear on the effort needed to make specified modifications.

Analyzability
Changeability
Stability
Testability
Maintainability Compliance

Portability - A set of attributes that bear on the ability of software to be transferred from one environment to another.

Adaptability
Install ability
Co-Existence
Replace ability
Portability Compliance

Each quality sub-characteristic (e.g. adaptability) is further divided into attributes. An attribute is an entity which can be verified or measured in the software product. Attributes are not defined in the standard, as they vary between different software products.

Software product is defined in a broad sense: it encompasses executables, source code, architecture descriptions, and so on. As a result, the notion of user extends to operators as well as to programmers, which are users of components such as software libraries.

The standard provides a framework for organizations to define a quality model for a software product. On doing so, however, it leaves up to each organization the task of specifying precisely its own model. This may be done, for example, by specifying target values for quality metrics which evaluates the degree of presence of quality attributes.

Internal Metrics

Internal metrics are those which do not rely on software execution (static measure)

External Metrics

External metrics are applicable to running software.

Quality in Use Metrics

Quality in use metrics are only available when the final product is used in real conditions. Ideally, the internal quality determines the external quality and external quality determines quality in use.

This standard stems from the GE model for describing software quality, presented in 1977 by McCall et al., which is organized around three types of Quality Characteristics:

Factors (To specify): They describe the external view of the software, as viewed by the users. Criteria (To build): They describe the internal view of the software, as seen by the developer. Metrics (To control): They are defined and used to provide a scale and method for measurement.

ISO/IEC 9126 distinguishes between a defect and a nonconformity, a defect being The nonfulfillment of intended usage requirements, whereas a nonconformity is The nonfulfillment of specified requirements. A similar distinction is made between validation and verification, known as V&V in the testing trade.

The following were incorrect answers:

Reliability - A set of attributes that bear on the capability of software to maintain its level of performance under stated conditions for a stated period of time.

Usability - A set of attributes that bear on the effort needed for use, and on the individual assessment of such use, by a stated or implied set of users.

Maintainability - A set of attributes that bear on the effort needed to make specified modifications.

CISA review manual 2014 Page number 188

QUESTION 81

Which of the following ACID property ensures that transaction will bring the database from one valid state to another?

- A. Atomicity
- B. Consistency
- C. Isolation
- D. Durability

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Consistency - The consistency property ensures that any transaction will bring the database from one valid state to another. Any data written to the database must be valid according to all defined rules, including but not limited to constraints, cascades, triggers, and any combination thereof. This does not guarantee correctness of the transaction in all ways the application programmer might have wanted (that is the responsibility of application-level code) but merely that any programming errors do not violate any defined rules.

For CISA exam you should know below information about ACID properties in DBMS:

Atomicity - Atomicity requires that each transaction is "all or nothing": if one part of the transaction fails, the

entire transaction fails, and the database state is left unchanged. An atomic system must guarantee atomicity in each and every situation, including power failures, errors, and crashes. To the outside world, a committed transaction appears (by its effects on the database) to be indivisible ("atomic"), and an aborted transaction does not happen.

Consistency - The consistency property ensures that any transaction will bring the database from one valid state to another. Any data written to the database must be valid according to all defined rules, including but not limited to constraints, cascades, triggers, and any combination thereof. This does not guarantee correctness of the transaction in all ways the application programmer might have wanted (that is the responsibility of application-level code) but merely that any programming errors do not violate any defined rules.

Isolation - The isolation property ensures that the concurrent execution of transactions results in a system state that would be obtained if transactions were executed serially, i.e. one after the other. Providing isolation is the main goal of concurrency control. Depending on concurrency control method, the effects of an incomplete transaction might not even be visible to another transaction.[citation needed]

Durability - Durability means that once a transaction has been committed, it will remain so, even in the event of power loss, crashes, or errors. In a relational database, for instance, once a group of SQL statements execute, the results need to be stored permanently (even if the database crashes immediately thereafter). To defend against power loss, transactions (or their effects) must be recorded in a non-volatile memory.

The following were incorrect answers:

Atomicity - Atomicity requires that each transaction is "all or nothing": if one part of the transaction fails, the entire transaction fails, and the database state is left unchanged.

Isolation - The isolation property ensures that the concurrent execution of transactions results in a system state that would be obtained if transactions were executed serially, i.e. one after the other.

Durability - Durability means that once a transaction has been committed, it will remain so, even in the event of power loss, crashes, or errors.
CISA review manual 2014 Page number 218

QUESTION 82

Which of the following ACID property in DBMS requires that each transaction is "all or nothing"?

- A. Atomicity
- B. Consistency
- C. Isolation
- D. Durability

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Atomicity requires that each transaction is "all or nothing": if one part of the transaction fails, the entire transaction fails, and the database state is left unchanged.

For CISA exam you should know below information about ACID properties in DBMS:

Atomicity - Atomicity requires that each transaction is "all or nothing": if one part of the transaction fails, the entire transaction fails, and the database state is left unchanged. An atomic system must guarantee atomicity

in each and every situation, including power failures, errors, and crashes. To the outside world, a committed transaction appears (by its effects on the database) to be indivisible ("atomic"), and an aborted transaction does not happen.

Consistency - The consistency property ensures that any transaction will bring the database from one valid state to another. Any data written to the database must be valid according to all defined rules, including but not limited to constraints, cascades, triggers, and any combination thereof. This does not guarantee correctness of the transaction in all ways the application programmer might have wanted (that is the responsibility of application-level code) but merely that any programming errors do not violate any defined rules.

Isolation - The isolation property ensures that the concurrent execution of transactions results in a system state that would be obtained if transactions were executed serially, i.e. one after the other. Providing isolation is the main goal of concurrency control. Depending on concurrency control method, the effects of an incomplete transaction might not even be visible to another transaction. [citation needed]

Durability - Durability means that once a transaction has been committed, it will remain so, even in the event of power loss, crashes, or errors. In a relational database, for instance, once a group of SQL statements execute, the results need to be stored permanently (even if the database crashes immediately thereafter). To defend against power loss, transactions (or their effects) must be recorded in a non-volatile memory.

The following were incorrect answers:

Consistency - The consistency property ensures that any transaction will bring the database from one valid state to another. Any data written to the database must be valid according to all defined rules, including but not limited to constraints, cascades, triggers, and any combination thereof. This does not guarantee correctness of the transaction in all ways the application programmer might have wanted (that is the responsibility of application-level code) but merely that any programming errors do not violate any defined rules.

Isolation - The isolation property ensures that the concurrent execution of transactions results in a system state that would be obtained if transactions were executed serially, i.e. one after the other.

Durability - Durability means that once a transaction has been committed, it will remain so, even in the event of power loss, crashes, or errors.
CISA review manual 2014 Page number 218

QUESTION 83

Which of the following ACID property in DBMS means that once a transaction has been committed, it will remain so, even in the event of power loss, crashes, or errors?

- A. Atomicity
- B. Consistency
- C. Isolation
- D. Durability

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Durability - Durability means that once a transaction has been committed, it will remain so, even in the event of power loss, crashes, or errors.

For CISA exam you should know below information about ACID properties in DBMS:

Atomicity - Atomicity requires that each transaction is "all or nothing": if one part of the transaction fails, the entire transaction fails, and the database state is left unchanged. An atomic system must guarantee atomicity in each and every situation, including power failures, errors, and crashes. To the outside world, a committed transaction appears (by its effects on the database) to be indivisible ("atomic"), and an aborted transaction does not happen.

Consistency - The consistency property ensures that any transaction will bring the database from one valid state to another. Any data written to the database must be valid according to all defined rules, including but not limited to constraints, cascades, triggers, and any combination thereof. This does not guarantee correctness of the transaction in all ways the application programmer might have wanted (that is the responsibility of application-level code) but merely that any programming errors do not violate any defined rules.

Isolation - The isolation property ensures that the concurrent execution of transactions results in a system state that would be obtained if transactions were executed serially, i.e. one after the other. Providing isolation is the main goal of concurrency control. Depending on concurrency control method, the effects of an incomplete transaction might not even be visible to another transaction. [citation needed]

Durability - Durability means that once a transaction has been committed, it will remain so, even in the event of power loss, crashes, or errors. In a relational database, for instance, once a group of SQL statements execute, the results need to be stored permanently (even if the database crashes immediately thereafter). To defend against power loss, transactions (or their effects) must be recorded in a non-volatile memory.

The following were incorrect answers:

Consistency - The consistency property ensures that any transaction will bring the database from one valid state to another. Any data written to the database must be valid according to all defined rules, including but not limited to constraints, cascades, triggers, and any combination thereof. This does not guarantee correctness of the transaction in all ways the application programmer might have wanted (that is the responsibility of application-level code) but merely that any programming errors do not violate any defined rules.

Isolation - The isolation property ensures that the concurrent execution of transactions results in a system state that would be obtained if transactions were executed serially, i.e. one after the other.

Atomicity requires that each transaction is "all or nothing": if one part of the transaction fails, the entire transaction fails, and the database state is left unchanged. CISA review manual 2014 Page number 218

QUESTION 84

Which of the following ACID property in DBMS ensures that the concurrent execution of transactions results in a system state that would be obtained if transactions were executed serially, i.e. one after the other?

- A. Atomicity
- B. Consistency
- C. Isolation
- D. Durability

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Isolation - The isolation property ensures that the concurrent execution of transactions results in a system

state that would be obtained if transactions were executed serially, i.e. one after the other.

For CISA exam you should know below information about ACID properties in DBMS:

Atomicity - Atomicity requires that each transaction is "all or nothing": if one part of the transaction fails, the entire transaction fails, and the database state is left unchanged. An atomic system must guarantee atomicity in each and every situation, including power failures, errors, and crashes. To the outside world, a committed transaction appears (by its effects on the database) to be indivisible ("atomic"), and an aborted transaction does not happen.

Consistency - The consistency property ensures that any transaction will bring the database from one valid state to another. Any data written to the database must be valid according to all defined rules, including but not limited to constraints, cascades, triggers, and any combination thereof. This does not guarantee correctness of the transaction in all ways the application programmer might have wanted (that is the responsibility of application-level code) but merely that any programming errors do not violate any defined rules.

Isolation - The isolation property ensures that the concurrent execution of transactions results in a system state that would be obtained if transactions were executed serially, i.e. one after the other. Providing isolation is the main goal of concurrency control. Depending on concurrency control method, the effects of an incomplete transaction might not even be visible to another transaction. [citation needed]

Durability - Durability means that once a transaction has been committed, it will remain so, even in the event of power loss, crashes, or errors. In a relational database, for instance, once a group of SQL statements execute, the results need to be stored permanently (even if the database crashes immediately thereafter). To defend against power loss, transactions (or their effects) must be recorded in a non-volatile memory.

The following were incorrect answers:

Consistency - The consistency property ensures that any transaction will bring the database from one valid state to another. Any data written to the database must be valid according to all defined rules, including but not limited to constraints, cascades, triggers, and any combination thereof. This does not guarantee correctness of the transaction in all ways the application programmer might have wanted (that is the responsibility of application-level code) but merely that any programming errors do not violate any defined rules.

Durability - Durability means that once a transaction has been committed, it will remain so, even in the event of power loss, crashes, or errors.

Atomicity requires that each transaction is "all or nothing": if one part of the transaction fails, the entire transaction fails, and the database state is left unchanged. CISA review manual 2014 Page number 218

QUESTION 85

Which of the following software development methods is based on iterative and incremental development, where requirements and solutions evolve through collaboration between self-organizing, cross-functional teams?

- A. Agile Development
- B. Software prototyping
- C. Rapid application development
- D. Component based development

Correct Answer: A

Explanation

Explanation/Reference:

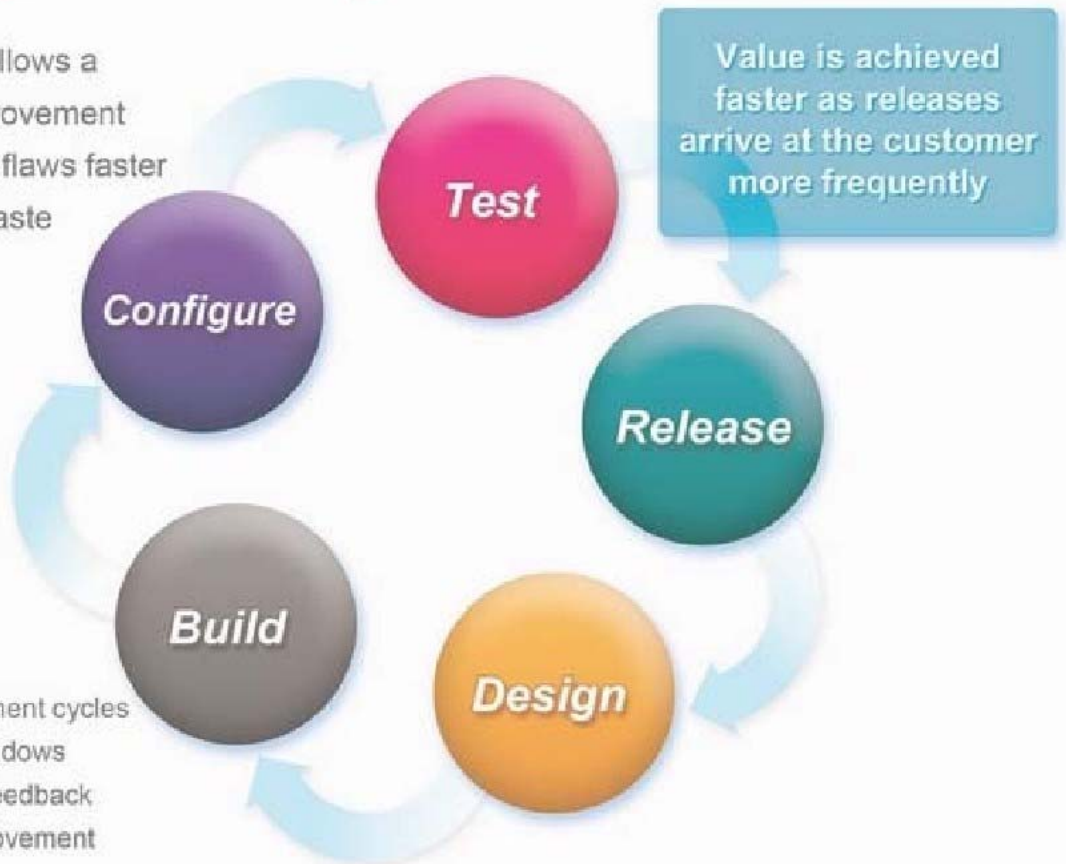
Section: Information System Acquisition, Development and Implementation For your exam you should know below information about agile development:

Agile software development is a group of software development methods based on iterative and incremental development, where requirements and solutions evolve through collaboration between self-organizing, cross-functional teams. It promotes adaptive planning, evolutionary development and delivery, a time-boxed iterative approach, and encourages rapid and flexible response to change. It is a conceptual framework that promotes foreseen tight iterations throughout the development cycle.

Agile Development

Agile Development Process

Development follows a continuous improvement cycle, exposing flaws faster and reducing waste



Advantage:

- Shorter development cycles
- Wider market windows
- Early customer feedback
- Continuous improvement

The Agile Manifesto introduced the term in 2001. Since then, the Agile Movement, with all its values, principles, methods, practices, tools, champions and practitioners, philosophies and cultures, has significantly changed the landscape of the modern software engineering and commercial software development in the Internet era.

Agile principles

The Agile Manifesto is based on twelve principles:

Customer satisfaction by rapid delivery of useful software
Welcome changing requirements, even late in development
Working software is delivered frequently (weeks rather than months)
Close, daily cooperation between business people and developers
Projects are built around motivated individuals, who should be trusted
Face-to-face conversation is the best form of communication (co-location)
Working software is the principal measure of progress
Sustainable development, able to maintain a constant pace
Continuous attention to technical excellence and good design
Simplicity--the art of maximizing the amount of work not done--is essential
Self-organizing teams
Regular adaptation to changing circumstances

What is Scrum?

Scrum is the most popular way of introducing Agility due to its simplicity and flexibility. Because of this popularity, many organizations claim to be "doing Scrum" but aren't doing anything close to Scrum's actual definition. Scrum emphasizes empirical feedback, team self-management, and striving to build properly tested product increments within short iterations. Doing Scrum as it's actually defined usually comes into conflict with existing habits at established non-Agile organizations.

The following were incorrect answers:

Software prototyping- Software prototyping, refers to the activity of creating prototypes of software applications, i.e., incomplete versions of the software program being developed. It is an activity that can occur in software development and is comparable to prototyping as known from other fields, such as mechanical engineering or manufacturing.

Rapid application development (RAD) is a software development methodology that uses minimal planning in favor of rapid prototyping. The "planning" of software developed using RAD is interleaved with writing the software itself. The lack of extensive per-planning generally allows software to be written much faster, and makes it easier to change requirements.

Component Based Development - It is a reuse-based approach to defining, implementing and composing loosely coupled independent components into systems. This practice aims to bring about an equally wide- ranging degree of benefits in both the short-term and the long-term for the software itself and for organizations that sponsor such software.

CISA review manual 2014 Page number 194

QUESTION 86

Which of the following software development methodology is a reuse-based approach to defining, implementing and composing loosely coupled independent components into systems?

A. Agile Developments

- B. Software prototyping
- C. Rapid application development
- D. Component based development

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Component-based software engineering (CBSE) (also known as component-based development (CBD)) is a branch of software engineering that emphasizes the separation of concerns in respect of the wide-ranging functionality available throughout a given software system. It is a reuse-based approach to defining, implementing and composing loosely coupled independent components into systems. This practice aims to bring about an equally wide-ranging degree of benefits in both the short-term and the long-term for the software itself and for organizations that sponsor such software.

Software engineers[who?] regard components as part of the starting platform for service-orientation. Components play this role, for example, in web services, and more recently, in service-oriented architectures (SOA), whereby a component is converted by the web service into a service and subsequently inherits further characteristics beyond that of an ordinary component.

Components can produce or consume events and can be used for event-driven architectures (EDA).

Definition and characteristics of components

An individual software component is a software package, a web service, a web resource, or a module that encapsulates a set of related functions (or data). All system processes are placed into separate components so that all of the data and functions inside each component are semantically related (just as with the contents of classes). Because of this principle, it is often said that components are modular and cohesive.

With regard to system-wide co-ordination, components communicate with each other via interfaces. When a component offers services to the rest of the system, it adopts a provided interface that specifies the services that other components can utilize, and how they can do so. This interface can be seen as a signature of the component - the client does not need to know about the inner workings of the component (implementation) in order to make use of it. This principle results in components referred to as encapsulated. The UML illustrations within this article represent provided interfaces by a lollipop-symbol attached to the outer edge of the component.

However, when a component needs to use another component in order to function, it adopts a used interface that specifies the services that it needs. In the UML illustrations in this article, used interfaces are represented by an open socket symbol attached to the outer edge of the component. A simple example of several software components - pictured within a hypothetical holiday-reservation system represented in UML 2.0.

Another important attribute of components is that they are substitutable, so that a component can replace another (at design time or run-time), if the successor component meets the requirements of the initial component (expressed via the interfaces). Consequently, components can be replaced with either an updated version or an alternative without breaking the system in which the component operates.

As a general rule of thumb for engineers substituting components, component B can immediately replace component A, if component B provides at least what component A provided and uses no more than what component A used.

Software components often take the form of objects (not classes) or collections of objects (from object-oriented programming), in some binary or textual form, adhering to some interface description language (IDL) so that the component may exist autonomously from other components in a computer.

When a component is to be accessed or shared across execution contexts or network links, techniques such as serialization or marshalling are often employed to deliver the component to its destination.

Reusability is an important characteristic of a high-quality software component. Programmers should design and implement software components in such a way that many different programs can reuse them.

Furthermore, component-based usability testing should be considered when software components directly interact with users.

It takes significant effort and awareness to write a software component that is effectively reusable. The component needs to be:

fully documented
thoroughly tested
robust - with comprehensive input-validity checking
able to pass back appropriate error messages or return codes
designed with an awareness that it will be put to unforeseen uses

The following were incorrect answers:

Agile Development - Agile software development is a group of software development methods based on iterative and incremental development, where requirements and solutions evolve through collaboration between self-organizing, cross-functional teams.

Software prototyping- Software prototyping, refers to the activity of creating prototypes of software applications, i.e., incomplete versions of the software program being developed. It is an activity that can occur in software development and is comparable to prototyping as known from other fields, such as mechanical engineering or manufacturing.

Rapid application development (RAD) is a software development methodology that uses minimal planning in favor of rapid prototyping. The "planning" of software developed using RAD is interleaved with writing the software itself. The lack of extensive per-planning generally allows software to be written much faster, and makes it easier to change requirements.

CISA review manual 2014 Page number 194

QUESTION 87

Which of the following software development methodology uses minimal planning and in favor of rapid prototyping?

- A. Agile Developments
- B. Software prototyping
- C. Rapid application development
- D. Component based development

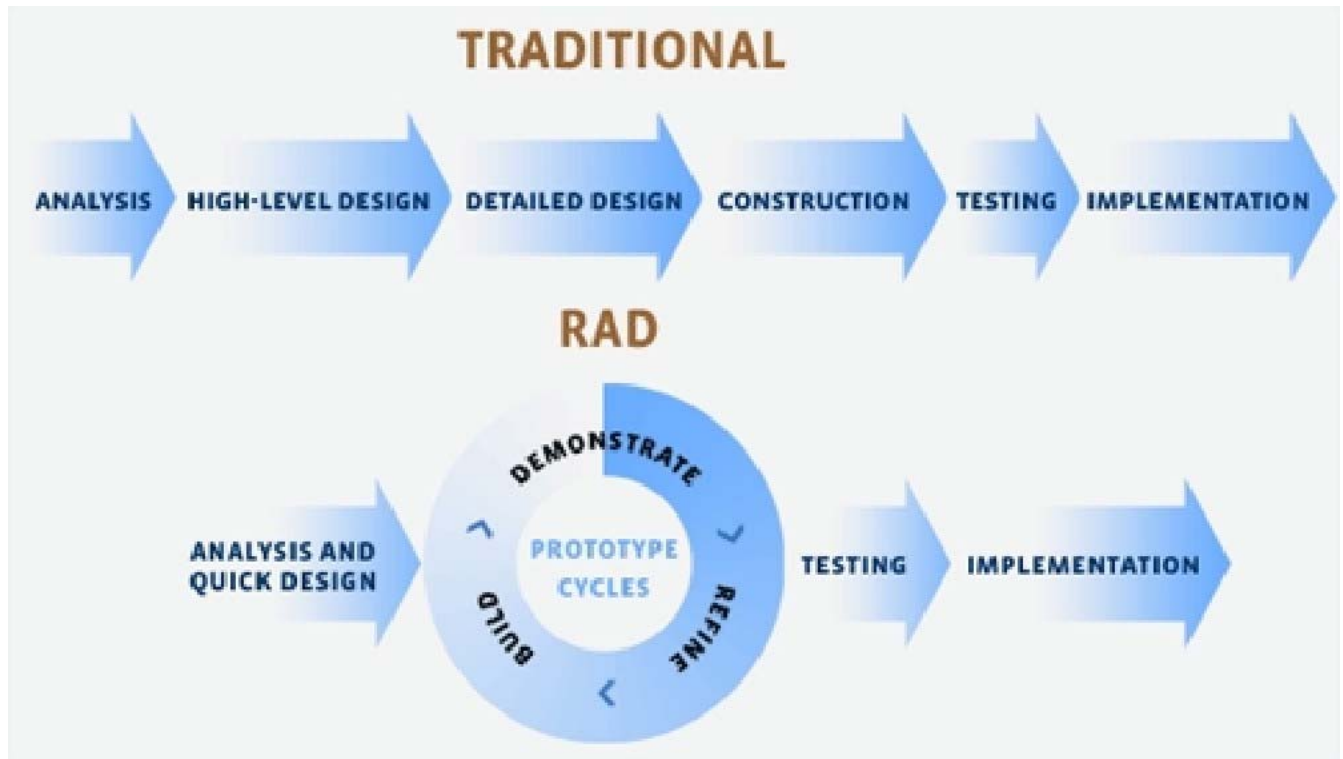
Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Rapid application development (RAD) is a software development methodology that uses minimal planning in favor of rapid prototyping. The "planning" of software developed using RAD is interleaved with writing the software itself. The lack of extensive per-planning generally allows software to be written much faster, and makes it easier to change requirements.

Rapid Application Development



Four phases of RAD

Requirements Planning phase combines elements of the system planning and systems analysis phases of the Systems Development Life Cycle (SDLC). Users, managers, and IT staff members discuss and agree on business needs, project scope, constraints, and system requirements. It ends when the team agrees on the key issues and obtains management authorization to continue.

User design phase during this phase, users interact with systems analysts and develop models and prototypes that represent all system processes, inputs, and outputs. The RAD groups or subgroups typically use a combination of Joint Application Development (JAD) techniques and CASE tools to translate user needs into working models. User Design is a continuous interactive process that allows users to understand, modify, and eventually approve a working model of the system that meets their needs.

Construction phase focuses on program and application development task similar to the SDLC. In RAD, however, users continue to participate and can still suggest changes or improvements as actual screens or reports are developed. Its tasks are programming and application development, coding, unit-integration and system testing.

Cutover phase resembles the final tasks in the SDLC implementation phase, including data conversion, testing, changeover to the new system, and user training. Compared with traditional methods, the entire process is compressed. As a result, the new system is built, delivered, and placed in operation much sooner.

The following were incorrect answers:

Agile Development - Agile software development is a group of software development methods based on iterative and incremental development, where requirements and solutions evolve through collaboration between self-organizing, cross-functional teams.

Software prototyping- Software prototyping, refers to the activity of creating prototypes of software applications, i.e., incomplete versions of the software program being developed. It is an activity that can occur in software development and is comparable to prototyping as known from other fields, such as mechanical engineering or manufacturing.

Component Based Development - It is a reuse-based approach to defining, implementing and composing loosely coupled independent components into systems. This practice aims to bring about an equally wide- ranging degree of benefits in both the short-term and the long-term for the software itself and for organizations that sponsor such software.

CISA review manual 2014 Page number 195

QUESTION 88

Which of the following is an estimation technique where the results can be measure by the functional size of

an information system based on the number and complexity of input, output, interface and queries?

- A. Functional Point analysis
- B. Gantt Chart
- C. Time box management
- D. Critical path methodology

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation For CISA exam you should know below information about Functional Point Analysis:

Function Point Analysis (FPA) is an ISO recognized method to measure the functional size of an information system. The functional size reflects the amount of functionality that is relevant to and recognized by the user in the business. It is independent of the technology used to implement the system.

The unit of measurement is "function points". So, FPA expresses the functional size of an information system in a number of function points (for example: the size of a system is 314 fop's).

The functional size may be used:

To budget application development or enhancement costs

To budget the annual maintenance costs of the application portfolio To determine project productivity after completion of the project To determine the Software

Size for cost estimating

All software applications will have numerous elementary processes or independent processes to move data. Transactions (or elementary processes) that bring data from outside the application domain (or application boundary) to inside that application boundary are referred to as external inputs. Transactions (or elementary processes) that take data from a resting position (normally on a file) to outside the application domain (or application boundary) are referred to as either an external outputs or external inquiries. Data at rest that is maintained by the application in question is classified as internal logical files. Data at rest that is maintained by another application in question is classified as external interface files.

Types of Function Point Counts:

Development Project Function Point Count

Function Points can be counted at all phases of a development project from requirements up to and including implementation. This type of count is associated with new development work. Scope creep can be tracked and monitored by understanding the functional size at all phase of a project. Frequently, this type of count is called a baseline function point count.

Enhancement Project Function Point Count

It is common to enhance software after it has been placed into production. This type of function point count tries to size enhancement projects. All production applications evolve over time. By tracking enhancement size and associated costs a historical database for your organization can be built. Additionally, it is important to understand how a Development project has changed over time.

Application Function Point Count

Application counts are done on existing production applications. This "baseline count" can be used with overall application metrics like total maintenance hours. This metric can be used to track maintenance hours per function point. This is an example of a normalized metric. It is not enough to examine only maintenance, but one must examine the ratio of maintenance hours to size of the application to get a true picture.

Productivity:

The definition of productivity is the output-input ratio within a time period with due consideration for quality. Productivity = outputs/inputs (within a time period, quality considered)

The formula indicates that productivity can be improved by (1) by increasing outputs with the same inputs, (2) by decreasing inputs but maintaining the same outputs, or (3) by increasing outputs and decreasing inputs change the ratio favorably.

Software Productivity = Function Points / Inputs

Effectiveness vs. Efficiency:

Productivity implies effectiveness and efficiency in individual and organizational performance. Effectiveness is the achievement of objectives. Efficiency is the achievement of the ends with least amount of resources.

Software productivity is defined as hours/function points or function points/hours. This is the average cost to develop software or the unit cost of software. One thing to keep in mind is the unit cost of software is not fixed with size. What industry data shows is the unit cost of software goes up with size.

Average cost is the total cost of producing a particular quantity of output divided by that quantity. In this case to Total Cost/Function Points. Marginal cost is the change in total cost attributable to a one-unit change in output.

There are a variety of reasons why marginal costs for software increase as size increases. The following is a list of some of the reasons

As size becomes larger complexity increases.

As size becomes larger a greater number of tasks need to be completed. As size becomes larger there is a greater number of staff members and they become more difficult to manage.

Function Points are the output of the software development process. Function points are the unit of software. It is very important to understand that Function Points remain constant regardless who develops the software or what language the software is developed in. Unit costs need to be examined very closely. To calculate average unit cost all items (units) are combined and divided by the total cost. On the other hand, to accurately estimate the cost of an application each component cost needs to be estimated.

Determine type of function point count

Determine the application boundary

Identify and rate transactional function types to determine their contribution to the unadjusted function point count.

Identify and rate data function types to determine their contribution to the unadjusted function point count.

Determine the value adjustment factor (VAF)

Calculate the adjusted function point count.

To complete a function point count knowledge of function point rules and application documentation is needed. Access to an application expert can improve the quality of the count. Once the application boundary has been established, FPA can be broken into three major parts

FPA for transactional function types

FPA for data function types

FPA for GSCs

Rating of transactions is dependent on both information contained in the transactions and the number of files referenced, it is recommended that transactions are counted first. At the same time a tally should be kept of all FTR's (file types referenced) that the transactions reference. Every FTR must have at least one or more transactions. Each transaction must be an elementary process. An elementary process is the smallest unit of activity that is meaningful to the end user in the business. It must be self-contained and leave the business in consistent state

The following were incorrect answers:

Critical Path Methodology - The critical path method (CPM) is an algorithm for scheduling a set of project activities

Gantt Chart - A Gantt chart is a type of bar chart, developed by Henry Gantt in the 1910s, that illustrates a project schedule. Gantt charts illustrate the start and finish dates of the terminal elements and summary elements of a project. Terminal elements and summary elements comprise the work breakdown structure of the project. Modern Gantt charts also show the dependency (i.e. precedence network) relationships between activities. Gantt charts can be used to show current schedule status using percent-complete shadings and a vertical "TODAY" line as shown here.

Time box Management - In time management, a time boxing allocates a fixed time period, called a time box, to each planned activity. Several project management approaches use time boxing. It is also used for individual use to address personal tasks in a smaller time frame. It often involves having deliverables and deadlines, which will improve the productivity of the user.

CISA review manual 2014 Page number 154

QUESTION 89

Which of the following is a project management technique for defining and deploying software deliverables within a relatively short and fixed period of time, and with predetermined specific resources?

- A. Functional Point analysis
- B. Gantt Chart
- C. Critical path methodology

D. Time box management

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Time box management is a project management technique for defining and deploying software deliverables within a relatively short and fixed period of time, and with predetermined specific resources. There is a need to balance software quality and meet the delivery requirements within the time box or timeframe. The project manager has some degree of flexibility and uses discretion in scoping the requirement. Timebox management can be used to accomplish prototyping or RAPID application development type in which key feature are to be delivered in a short period of time.

The following were incorrect answers:

Critical path Method -The critical path method (CPM) is an algorithm for scheduling a set of project activities Gantt Chart -A Gantt chart is a type of bar chart, developed by Henry Gantt in the 1910s, that illustrates a project schedule. Gantt charts illustrate the start and finish dates of the terminal elements and summary elements of a project. Terminal elements and summary elements comprise the work breakdown structure of the project. Modern Gantt charts also show the dependency (i.e. precedence network) relationships between activities. Gantt charts can be used to show current schedule status using percent-complete shadings and a vertical "TODAY" line as shown here.

Functional Point Analysis -Function Point Analysis (FPA) is an ISO recognized method to measure the functional size of an information system. The functional size reflects the amount of functionality that is relevant to and recognized by the user in the business. It is independent of the technology used to implement the system.

CISA review manual 2014 Page number 154

QUESTION 90

Who is mainly responsible for protecting information assets they have been entrusted with on a daily basis by defining who can access the data, it's sensitivity level, type of access, and adhering to corporate information security policies?

- A. Data Owner
- B. Security Officer
- C. Senior Management
- D. End User

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation The Data Owner is the person who has been entrusted with a data set that belong to the company. As such they are responsible to classify the data according to it's value and sensitivity. The Data Owner decides who will get access to the data, what type of access would be granted. The Data Owner will tell the Data Custodian or System Administrator what access to configure within the systems.

A business executive or manager is typically responsible for an information asset. These are the individuals that assign the appropriate classification to information assets. They ensure that the business information is protected with appropriate controls. Periodically, the information asset owners need to review the classification and access rights associated with information assets. The owners, or their delegates, may be required to approve access to the information. Owners also need to determine the criticality, sensitivity, retention, backups, and safeguards for the information. Owners or their delegates are responsible for understanding the risks that exist with regards to the information that they control.

The following answers are incorrect:

Executive Management/Senior Management - Executive management maintains the overall responsibility for protection of the information assets. The business operations are dependent upon information being available, accurate, and protected from individuals without a need to know.

Security Officer - The security officer directs, coordinates, plans, and organizes information security activities throughout the organization. The security officer works with many different individuals, such as executive management, management of the business units, technical staff, business partners, auditors, and third parties such as vendors. The security officer and his or her team are responsible for the design, implementation, management, and review of the organization's security policies, standards, procedures, baselines, and guidelines.

End User - The end user does not decide on classification of the data CISA review manual 2014 page number 108

Official ISC2 guide to CISSP CBK 3rd Edition Page number 342

QUESTION 91

Which of the following testing method examines the functionality of an application without peering into its internal structure or knowing the details of it's internals?

- A. Black-box testing
- B. Parallel Test
- C. Regression Testing
- D. Pilot Testing

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation Black-box testing is a method of software testing that examines the functionality of an application (e.g. what the software does) without peering into its internal structures or workings (see white-box testing). This method of test can be applied to virtually every level of software testing: unit, integration, system and acceptance. It typically comprises most if not all higher level testing, but can also dominate unit testing as well.

For your exam you should know the information below:

Alpha and Beta Testing - An alpha version is early version of the application system submitted to the internal user for testing. The alpha version may not contain all the features planned for the final version. Typically, software goes to two stages testing before it consider finished. The first stage is called alpha testing is often performed only by the user within the organization developing the software. The second stage is called beta testing, a form of user acceptance testing, generally involves a limited number of external users. Beta testing is the last stage of testing, and normally involves real world exposure, sending the beta version of the product to independent beta test sites or offering it free to interested user.

Pilot Testing -A preliminary test that focuses on specific and predefined aspect of a system. It is not meant to replace other testing methods, but rather to provide a limited evaluation of the system. Proof of concept are early pilot tests usually over interim platform and with only basic functionalities.

White box testing - Assess the effectiveness of a software program logic. Specifically, test data are used in determining procedural accuracy or conditions of a program's specific logic path. However, testing all possible logical path in large information system is not feasible and would be cost prohibitive, and therefore is used on selective basis only.

Black Box Testing - An integrity based form of testing associated with testing components of an information system's "functional" operating effectiveness without regards to any specific internal program structure.
Applicable to integration and user acceptance testing.

Function/validation testing It is similar to system testing but it is often used to test the functionality of the system against the detailed requirements to ensure that the software that has been built is traceable to customer requirements.

Regression Testing -The process of rerunning a portion of a test scenario or test plan to ensure that changes or corrections have not introduced new errors. The data used in regression testing should be same as original data.

Parallel Testing - This is the process of feeding test data into two systems the modified system and an alternative system and comparing the result.

Sociability Testing -The purpose of these tests is to confirm that new or modified system can operate in its target environment without adversely impacting existing system. This should cover not only platform that will perform primary application processing and interface with other system but, in a client server and web development, changes to the desktop environment. Multiple application may run on the user's desktop, potentially simultaneously, so it is important to test the impact of installing new dynamic link libraries (DLLs), making operating system registry or configuration file modification, and possibly extra memory utilization.

The following answers are incorrect:

Parallel Testing - This is the process of feeding test data into two systems the modified system and an alternative system and comparing the result.

Regression Testing -The process of rerunning a portion of a test scenario or test plan to ensure that changes or corrections have not introduced new errors. The data used in regression testing should be same as original data.

Pilot Testing -A preliminary test that focuses on specific and predefined aspect of a system. It is not meant to replace other testing methods, but rather to provide a limited evaluation of the system. Proof of concept are early pilot tests usually over interim platform and with only basic functionalities CISA review manual 2014 Page number 167
Official ISC2 guide to CISSP CBK 3rd Edition Page number 176

QUESTION 92

Which of the following testing method examines internal structure or working of an application?

- A. White-box testing
- B. Parallel Test
- C. Regression Testing
- D. Pilot Testing

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation White-box testing (also known as clear box testing, glass box testing, transparent box testing, and structural testing) is a method of testing software that tests internal structures or workings of an application, as opposed to its functionality (i.e. black-box testing). In white-box testing an internal perspective of the system, as well as programming skills, are used to design test cases. The tester chooses inputs to exercise paths through the code and determine the appropriate outputs. This is analogous to testing nodes in a circuit, e.g. in-circuit testing (ICT).

White-box testing can be applied at the unit, integration and system levels of the software testing process. Although traditional testers tended to think of white-box testing as being done at the unit level, it is used for integration and system testing more frequently today. It can test paths within a unit, paths between units during integration, and between subsystems during a systemlevel test. Though this method of test design can uncover many errors or problems, it has the potential to miss unimplemented parts of the specification or missing requirements.
For your exam you should know the information below:

Alpha and Beta Testing - An alpha version is early version is an early version of the application system submitted to the internal user for testing. The alpha version may not contain all the features planned for the final version. Typically, software goes to two stages testing before it consider finished. The first stage is called alpha testing is often performed only by the user within the organization developing the software. The second stage is called beta testing, a form of user acceptance testing, generally involves a limited number of external users. Beta testing is the last stage of testing, and normally involves real world exposure, sending the beta version of the product to independent beta test sites or offering it free to interested user.

Pilot Testing -A preliminary test that focuses on specific and predefined aspect of a system. It is not meant to replace other testing methods, but rather to provide a limited evaluation of the system. Proof of concept are early pilot tests usually over interim platform and with only basic functionalities.

White box testing - Assess the effectiveness of a software program logic. Specifically, test data are used in determining procedural accuracy or conditions of a program's specific logic path. However, testing all possible logical path in large information system is not feasible and would be cost prohibitive, and therefore is used on selective basis only.

Black Box Testing - An integrity based form of testing associated with testing components of an information system's "functional" operating effectiveness without regards to any specific internal program structure.
Applicable to integration and user acceptance testing.

Function/validation testing It is similar to system testing but it is often used to test the functionality of the system against the detailed requirements to ensure that the software that has been built is traceable to customer requirements.

Regression Testing -The process of rerunning a portion of a test scenario or test plan to ensure that changes or corrections have not introduced new errors. The data used in regression testing should be same as original data.

Parallel Testing - This is the process of feeding test data into two systems the modified system and an alternative system and comparing the result.

Sociability Testing -The purpose of these tests is to confirm that new or modified system can operate in its target environment without adversely impacting existing system. This should cover not only platform that will perform primary application processing and interface with other system but, in a client server and web development, changes to the desktop environment. Multiple application may run on the user's desktop, potentially simultaneously, so it is important to test the impact of installing new dynamic link libraries (DLLs), making operating system registry or configuration file modification, and possibly extra memory utilization.

The following answers are incorrect:

Parallel Testing - This is the process of feeding test data into two systems the modified system and an alternative system and comparing the result.

Regression Testing -The process of rerunning a portion of a test scenario or test plan to ensure that changes or corrections have not introduced new errors. The data used in regression testing should be same as original data.

Pilot Testing -A preliminary test that focuses on specific and predefined aspect of a system. It is not meant to replace other testing methods, but rather to provide a limited evaluation of the system. Proof of concept are early pilot tests usually over interim platform and with only basic functionalities CISA review manual 2014 Page number 167
Official ISC2 guide to CISSP CBK 3rd Edition Page number 176

QUESTION 93

Identify the correct sequence of Business Process Reengineering (BPR) benchmarking process from the given choices below?

- A. PLAN, RESEARCH, OBSERVE, ANALYZE, ADOPT and IMPROVE
- B. OBSERVE, PLAN, RESEARCH, ANALYZE, ADOPT and IMPROVE
- C. PLAN, OBSERVE, RESEARCH, ANALYZE, ADOPT and IMPROVE
- D. PLAN, RESEARCH, ANALYZE, OBSERVE, ADOPT and IMPROVE

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation The correct sequence of BRP benchmarking is PLAN, RESEARCH, OBSERVE, ANALYZE, ADOPT and IMPROVE.

For your exam you should know the information below:

Overview of Business Process Reengineering

One of the principles in business that remains constant is the need to improve your processes and procedures. Most trade magazines today contain discussions of the detailed planning necessary for implementing change in an organization. The concept of change must be accepted as a fundamental principle. Terms such as business evolution and continuous improvement ricochet around the room in business meetings. It's a fact that organizations which fail to change are destined to perish.

As a CISA, you must be prepared to investigate whether process changes within the organization are accounted for with proper documentation. All internal control frameworks require that management be held responsible for safeguarding all the assets belonging to their organization. Management is also responsible for increasing revenue.

BPR Application Steps

ISACA cites six basic steps in their general approach to BPR. These six steps are simply an extension of Stewart's Plan-Do-Check-Act model for managing projects:

Envision -Visualize a need (envision). Develop an estimate of the ROI created by the proposed change. Elaborate on the benefit with a preliminary project plan to gain sponsorship from the organization. The plan should define the areas to be reviewed and clarify the desired result at the end of the project (aka end state objective). The deliverables of the envision phase include the following:

Project champion working with the steering committee to gain top management approval Brief description of project scope, goals, and objectives description of the specific deliverables from this project with a preliminary charter to evidence management's approval, the project may proceed into the initiation phase.

Initiate -This phase involves setting BPR goals with the sponsor. Focus on planning the collection of detailed evidence necessary to build the subsequent BPR plan for redesigning the process. Deliverables in the initiation phase include the following:

Identifying internal and external requirements (project specifications) Business case explaining why this project makes sense (justification) and the estimated return on investment compared to the total cost (net ROI)

Formal project plan with budget, schedule, staffing plan, procurement plan, deliverables, and project risk analysis

Level of authority the BPR project manager will hold and the composition of any support committee or task force that will be required

From the profit and loss (P&L) statement, identify the item line number that money will be debited from to pay for this project and identify the specific P&L line number that the financial return will later appear under (to provide strict monitoring of the ROI performance)

Formal project charter signed by the sponsors It's important to realize that some BPR projects will proceed to their planned conclusion and others may be halted because of insufficient evidence. After a plan is formally approved, the

BPR project may proceed to the diagnostic phase.

Diagnose Document existing processes. Now it's time to see what is working and identify the source of each requirement. Each process step is reviewed to calculate the value it creates. The goal of the diagnostic phase is to gain a better understanding of existing processes. The data collected in the diagnostic phase forms the basis of all planning decisions:

Detailed documentation of the existing process

Performance measurement of individual steps in the process

Evidence of specific process steps that add customer value

Identification of process steps that don't add value

Definition of attributes that create value and quality

Put in the extra effort to do a good job of collecting and analyzing the evidence. All future assumptions will be

based on evidence from the diagnostic phase.

Redesign- Using the evidence from the diagnostic phase, it's time to develop the new process. This will take several planning iterations to ensure that the strategic objectives are met. The formal redesign plans will be reviewed by sponsors and stakeholders. A final plan will be presented to the steering committee for approval. Here's an example of deliverables from the redesign phase. Comparison of the envisioned objective to actual specifications Analysis of alternatives (AoA)

Prototyping and testing of the redesigned process

Formal documentation of the final design

The project will need formal approval to proceed into the reconstruction phase. Otherwise, the redesign is halted pending further scrutiny while comparing the proposed design with available evidence. Insufficient evidence warrants halting the project.

Reconstruct With formal approval received, it's time to begin the implementation phase. The current processes are deconstructed and reassembled according to the plan. Reconstruction may be in the form of a parallel process, modular changes, or complete transition. Each method presents a unique risk and reward opportunity. Deliverables from this phase include the following:

Conversion plan with dependencies in time sequence

Change control management

Execution of conversion plan with progress monitoring

Training of users and support personnel

Pilot implementation to ensure a smooth migration Formal approval by the sponsor. The reconstructed process must be formally approved by management to witness their consent for fitness of use. IT governance dictates that executive management shall be held responsible for any failures and receive recognition for exceptional results. System performance will be evaluated again after entering production use.

Evaluate (post evaluation) The reconstructed process is monitored to ensure that it works and is producing the strategic value as forecast in the original justification.

Comparison of original forecast to actual performance Identification of lessons learned Total quality management plan to maintain the new process

A method of continuous improvement is implemented to track the original goals against actual process performance. Annual reevaluation is needed to adapt new requirements or new opportunities.

Benchmarking as a BPR Tool

Benchmarking is the process of comparing performance data (aka metrics). It can be used to evaluate business processes that are under consideration for reengineering. Performance data may be obtained by using a self-assessment or by auditing for compliance against a standard (reference standard). Evidence captured during the diagnostic phase is considered the key to identifying areas for performance improvement and documenting obstacles. ISACA offers the following general guidelines for performing benchmarks:

Plan Identify the critical processes and create measurement techniques to grade the processes. Research Use information about the process and collect regular data (samples) to build a baseline for comparison. Consider input from your customers and use analogous data from other industries. Observe Gather internal

data and external data from a benchmark partner to aid the comparison results. Benchmark data can also be compared against published standards. Analyze Look for root cause-effect relationships and other dependencies in the process. Use predefined tools and procedures to collate the data collected from all available sources. Adapt Translate the findings into hypotheses of how these findings will help or hurt strategic business goals.

Design a pilot test to prove or disprove the hypotheses.

Improve Implement a prototype of the new processes. Study the impact and note any unexpected results. Revise the process by using controlled change management. Measure the process results again. Use reestablished procedures such as total quality management for continuous improvement.

The following answers are incorrect:

The other options specified does not represent the correct sequence of BRP benchmarking steps.

CISA review manual 2014 page number 219 to 211

CISA certified information system auditor study guide Second Edition Page Number 154 to 158

QUESTION 94

Identify the correct sequence of Business Process Reengineering (BPR) application steps from the given choices below?

- A. Envision, Initiate, Diagnose, Redesign, Reconstruct and Evaluate
- B. Initiate, Envision, Diagnose, Redesign, Reconstruct and Evaluate
- C. Envision, Diagnose, Initiate, Redesign, Reconstruct and Evaluate
- D. Evaluate, Envision, Initiate, Diagnose, Redesign, Reconstruct

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation The correct sequence of BRP application step is Envision, Initiate, Diagnose, Redesign, Reconstruct and Evaluate.

For your exam you should know the information below:

Overview of Business Process Reengineering

One of the principles in business that remains constant is the need to improve your processes and procedures. Most trade magazines today contain discussions of the detailed planning necessary for implementing change in an organization. The concept of change must be accepted as a fundamental principle. Terms such as business evolution and continuous improvement ricochet around the room in business meetings. It's a fact that organizations which fail to change are destined to perish.

As a CISA, you must be prepared to investigate whether process changes within the organization are accounted for with proper documentation. All internal control frameworks require that management be held responsible for safeguarding all the assets belonging to their organization. Management is also responsible for increasing revenue.

BPR Application Steps

ISACA cites six basic steps in their general approach to BPR. These six steps are simply an extension of Stewart's Plan-Do-Check-Act model for managing projects:

Envision -Visualize a need (envision). Develop an estimate of the ROI created by the proposed change. Elaborate on the benefit with a preliminary project plan to gain sponsorship from the organization. The plan should define the areas to be reviewed and clarify the desired result at the end of the project (aka end state objective). The deliverables of the envision phase include the following:

Project champion working with the steering committee to gain top management approval Brief description of project scope, goals, and objectives description of the specific deliverables from this project with a preliminary charter to evidence management's approval, the project may proceed into the initiation phase.

Initiate -This phase involves setting BPR goals with the sponsor. Focus on planning the collection of detailed evidence necessary to build the subsequent BPR plan for redesigning the process. Deliverables in the initiation phase include the following:

Identifying internal and external requirements (project specifications) Business case explaining why this project makes sense (justification) and the estimated return on investment compared to the total cost (net ROI)

Formal project plan with budget, schedule, staffing plan, procurement plan, deliverables, and project risk

analysis

Level of authority the BPR project manager will hold and the composition of any support committee or task force that will be required

From the profit and loss (P&L) statement, identify the item line number that money will be debited from to pay for this project and identify the specific P&L line number that the financial return will later appear under (to provide strict monitoring of the ROI performance)

Formal project charter signed by the sponsors

It's important to realize that some BPR projects will proceed to their planned conclusion and others may be halted because of insufficient evidence. After a plan is formally approved, the BPR project may proceed to the diagnostic phase.

Diagnose Document existing processes. Now it's time to see what is working and identify the source of each requirement. Each process step is reviewed to calculate the value it creates. The goal of the diagnostic phase is to gain a better understanding of existing processes. The data collected in the diagnostic phase forms the basis of all planning decisions:

Detailed documentation of the existing process

Performance measurement of individual steps in the process

Evidence of specific process steps that add customer value

Identification of process steps that don't add value

Definition of attributes that create value and quality

Put in the extra effort to do a good job of collecting and analyzing the evidence. All future assumptions will be based on evidence from the diagnostic phase.

Redesign- Using the evidence from the diagnostic phase, it's time to develop the new process. This will take several planning iterations to ensure that the strategic objectives are met. The formal redesign plans will be reviewed by sponsors and stakeholders. A final plan will be presented to the steering committee for approval. Here's an example of deliverables from the redesign phase.

Comparison of the envisioned objective to actual specifications Analysis of alternatives (AoA)

Prototyping and testing of the redesigned process

Formal documentation of the final design

The project will need formal approval to proceed into the reconstruction phase. Otherwise, the redesign is halted pending further scrutiny while comparing the proposed design with available evidence. Insufficient evidence warrants halting the project.

Reconstruct With formal approval received, it's time to begin the implementation phase. The current processes are deconstructed and reassembled according to the plan. Reconstruction may be in the form of a parallel process, modular changes, or complete transition. Each method presents a unique risk and reward opportunity. Deliverables from this phase include the following:

Conversion plan with dependencies in time sequence

Change control management

Execution of conversion plan with progress monitoring

Training of users and support personnel
Pilot implementation to ensure a smooth migration
Formal approval by the sponsor.

The reconstructed process must be formally approved by management to witness their consent for fitness of use. IT governance dictates that executive management shall be held responsible for any failures and receive recognition for exceptional results. System performance will be evaluated again after entering production use.

Evaluate (post evaluation) The reconstructed process is monitored to ensure that it works and is producing the strategic value as forecast in the original justification.

Comparison of original forecast to actual performance Identification of lessons learned

Total quality management plan to maintain the new process

A method of continuous improvement is implemented to track the original goals against actual process performance. Annual reevaluation is needed to adapt new requirements or new opportunities.

Benchmarking as a BPR Tool

Benchmarking is the process of comparing performance data (aka metrics). It can be used to evaluate business processes that are under consideration for reengineering. Performance data may be obtained by using a self-assessment or by auditing for compliance against a standard (reference standard). Evidence captured during the diagnostic phase is considered the key to identifying areas for performance improvement and documenting obstacles. ISACA offers the following general guidelines for performing benchmarks:

Plan Identify the critical processes and create measurement techniques to grade the processes. Research Use information about the process and collect regular data (samples) to build a baseline for comparison. Consider input from your customers and use analogous data from other industries. Observe Gather internal data and external data from a benchmark partner to aid the comparison results. Benchmark data can also be compared against published standards. Analyze Look for root cause-effect relationships and other dependencies in the process. Use predefined tools and procedures to collate the data collected from all available sources. Adapt Translate the findings into hypotheses of how these findings will help or hurt strategic business goals.

Design a pilot test to prove or disprove the hypotheses.

Improve Implement a prototype of the new processes. Study the impact and note any unexpected results. Revise the process by using controlled change management. Measure the process results again. Use reestablished procedures such as total quality management for continuous improvement.

The following answers are incorrect:

The other options specified does not represent the correct sequence of BRP application steps.

CISA review manual 2014 page number 219 to 211

CISA certified information system auditor study guide Second Edition Page Number 154 to 158

QUESTION 95

Following request for proposal (RFP) responses, a project seeking to acquire a new application system has identified a short list of vendors. At this point, the IS auditor should:

- A. encourage contact with current users of the vendor's products
- B. perform a detailed cost-benefit exercise on the proposed application
- C. require that contract terms include a right-to-audit clause
- D. recommend performing system integration tests

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 96

Following a recent acquisition, an information security manager has been requested the outstanding risk reported early in the acquisition process. Which of the following would be the manager's BEST course of action?

- A. Perform a vulnerability assessment of the acquired company's infrastructure.
- B. Re-evaluate the risk treatment plan for the outstanding risk.
- C. Re-assess the outstanding risk of the acquired company.
- D. Add the outstanding risk to the acquiring organization's risk registry

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 97

During the due diligence phase of an acquisition, the MOST important course of action for an information security manager would be to:

- A. review the state of security awareness
- B. perform a gap analysis
- C. perform a risk assessment
- D. review information security policies

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 98

When an organization and its IT-hosting service provider are establishing a contract with each other, it is MOST important that the contract includes:

- A. each party's security responsibilities
- B. details of expected security metrics
- C. penalties for noncompliance with security policy
- D. recovery time objectives (RTOs)

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 99

An organization is in the process of acquiring a competitor. The information security manager has been asked to report on the security posture of the target acquisition. Which of the following should be the security manager's FIRST course of action?

- A. Implement a security dashboard
- B. Quantify the potential risk
- C. Perform a gap analysis
- D. Perform a vulnerability assessment

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 100

A review of an organization's IT portfolio revealed several applications that are not in use. The BEST way to prevent this situation from recurring would be to implement:

- A. a formal request for proposal (RFP) process
- B. an information asset acquisition policy
- C. asset life cycle management
- D. business case development procedures

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 101

At which stage of the software development life cycle should an organization identity privacy considerations?

- A. Design
- B. Testing
- C. Development
- D. Requirements

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 102

An IS auditor determines that a business impact analysis (BIA) was not conducted during the development of a business continuity plan (BCP). What is the MOST significant risk that could result from this situation?

- A. Responsibilities are not properly defined.
- B. Recovery time objectives (RTOs) are not correctly determined.
- C. Key performance indicators (KPIs) are not aligned.
- D. Critical business applications are not covered.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 103

Which of the following is MOST important with regard to an application development acceptance test?

- A. The quality assurance (QA) team is in charge of the testing process.
- B. User management approves the test design before the test is started.
- C. The programming team is involved in the testing process.
- D. All data files are tested for valid information before conversion.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 104

A risk analysis is MOST useful when applied during which phase of the system development process?

- A. Pre-implementation
- B. Testing
- C. Design
- D. Feasibility

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 105

Which of the following would provide the MOST useful input to IS audit management when developing an action plan for improving internal audit's performance?

- A. Feedback from departments that have participated in IS audits
- B. Industry benchmarking analysis
- C. An external quality assessment review
- D. Results train an improvement initiative overseen by executive management

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 106

An organization has outsourced the development of a core application. However, the organization plans to bring the support and future maintenance of the application back in-house. Which of the following findings should be the IS auditor's GREATEST concern?

- A. A training plan for business users has not been developed.
- B. The cost of outsourcing is lower than in-house development.
- C. The vendor development team is located overseas.
- D. The data model is not clearly documented.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 107

Which of the following is the MOST important consideration when developing an incident response program?

- A. Senior management support
- B. Technical skills of response staff
- C. Number of dedicated response staff
- D. Incident response procedures

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 108

Which of the following stakeholders should be PRIMARILY responsible for developing, implementing, and monitoring metrics for security activities?

- A. Chief technology officer
- B. Security incident response team
- C. Chief information security officer
- D. IT steering committee

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 109

Incorporating the results of a maturity model assessment is MOST useful in the development of:

- A. balanced scorecards.
- B. strategic implementation plans.
- C. key performance indicators (KPIs).
- D. key risk indicators (KRIs).

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 110

Which of the following testing approaches provides the GREATEST assurance that only approved systems development releases have been implemented in the production environment?

- A. Test whether a sample of approved developments have releases in production migration logs.
- B. Test whether a sample of developments in the systems development register have documented approvals.
- C. Test whether a sample of releases in production migration logs have corresponding approvals.
- D. Test whether a sample of releases followed the organization's segregation of duties access.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 111

When developing a business continuity plan (BCP), which of the following steps should be completed FIRST?

- A. Ensure that offsite backups can be efficiently restored.
- B. Identify alternatives to critical applications.
- C. Review the business continuity insurance policy.
- D. Carry out a risk assessment.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 112

Which of the following is the BEST recommendation for the establishment of an information security policy?

- A. The policy should be developed by IS management.
- B. The development and approval should be overseen by business area management.
- C. The policy and guidelines should be developed by the human resources department.
- D. The policy should be developed by the security administrator.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 113

Which of the following is the BEST development methodology to help manage project requirements in a rapidly changing environment?

- A. Object-oriented system development
- B. Waterfall development process
- C. Iterative development process
- D. Prototyping

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 114

An IS auditor performing an application development review attends development team meetings. The IS auditor's independence will be compromised if the IS auditor:

- A. designs and executes the user's acceptance test plan.
- B. re-performs test procedures used by the development team.
- C. reviews the result of systems tests that were performed by the development team.
- D. assists in developing an integrated test facility (ITF) on the system.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 115

An IS auditor would be concerned if the quality assurance (QA) function were found to be performing which of the following roles?

- A. Reviewing the code to ensure proper documentation and development practices were followed
- B. Submitting corrected code for issues identified through the testing process
- C. Evaluating whether the testing assumptions and developed code are aligned to the design criteria
- D. Ensuring the development methods and standards are adhered to throughout the process

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 116

A new application will require multiple interfaces. Which of the following testing methods can be used to detect interface errors early in the development life cycle?

- A. Acceptance
- B. Top down
- C. Sociability
- D. Bottom up

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 117

An IS auditor is reviewing the release management process for an in-house software development solution. In

which environment is the software version MOST likely to be the same as production?

- A. Testing
- B. Development
- C. Integration
- D. Staging

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 118

An advantage of object-oriented system development is that it:

- A. partitions systems into a client/server architecture.
- B. decreases the need for system documentation.
- C. is easier to code than procedural languages.
- D. is suited to data with complex relationships.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 119

Which of the following is the BEST indication that a newly developed information system is ready for migration into production?

- A. Items in the work breakdown structure are completed.
- B. Audit has signed off.
- C. User acceptance testing is successfully completed.
- D. Technical requirements are met.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 120

An IS auditor finds that the cost of developing an application is now projected to significantly exceed the budget. Which of the following is the GREATEST risk to communicate to senior management?

- A. Increased staff turnover
- B. Project abandonment
- C. Noncompliance with project methodology
- D. Inability to achieve expected benefits

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 121

Which of the following would be an IS auditor's GREATEST concern when reviewing the early stages of a software development project?

- A. The lack of acceptance criteria behind user requirements
- B. The lack of completion of all requirements at the end of each sprint
- C. The lack of technical documentation to support the program code
- D. The lack of a detailed unit and system test plan

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 122

An organization is developing a web portal using some external components. Which of the following should be of MOST concern to an IS auditor?

- A. Open-source components were integrated during development.
- B. Some of the developers are located in another country.
- C. The organization has not reviewed the components for known exploits.
- D. Staff require additional training in order to perform code review.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 123

Which of the following is the BEST indication of control maturity in an organization's systems development and implementation processes?

- A. Code changes are tested and deployed manually.
- B. Code changes are deployed to a test server and then to production.
- C. Code changes are documented and approved.
- D. Code changes are tested and deployed through automation.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 124

Which of the following is the MOST important consideration when developing an online business architecture and recovery strategy?

- A. Vendors' network security
- B. Immediate problem resolution
- C. Vendors' financial stability
- D. Single points of failure

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 125

When initiating an IT project, which of the following should be completed FIRST?

- A. Project plan
- B. Request for proposal
- C. Feasibility study
- D. Requirements definition

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 126

Which of the following BEST supports an organization's planning efforts for investments in IT initiatives?

- A. Capability maturity model
- B. Enterprise architecture
- C. Agile project management
- D. Continuous gap assessment

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 127

When designing a data analytics process, which of the following should be the stakeholder's role in automating data extraction and validation?

- A. Performing the business case analysis for the data analytics initiative
- B. Indicating which data elements are necessary to make informed decisions
- C. Designing the workflow necessary for the data analytics tool to evaluate the appropriate data
- D. Allocating the resources necessary to purchase the appropriate software packages

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 128

As part of a quality assurance initiative, an organization has engaged an external auditor to evaluate the internal IS audit function. Which of the following observations should be of MOST concern?

- A. Audit reports are not approved by the audit committee.
- B. Audit reports do not state they are conducted in accordance with industry standards.
- C. The audit team is not sufficiently leveraging data analytics.
- D. Audit engagements are not risk-based.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 129

Which of the following is the BEST way to help ensure new IT implementations align with enterprise architecture principles and requirements?

- A. Conduct enterprise architecture reviews as part of the change advisory board.

- B. Consider stakeholder concerns when defining the enterprise architecture.
- C. Document the security view as part of the enterprise architecture.
- D. Perform mandatory post-implementation reviews of IT implementations

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 130

Which of the following is MOST important for the successful completion of a new application system?

- A. Appropriate training of system analysts
- B. Steering committee approval of the new system
- C. Completion of a positive cost-benefit analysis
- D. User participation in the project development

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 131

An IS auditor was involved in the design phase for a new system's security architecture. For the planned post-implementation audit, which of the following would be the MOST appropriate course of action for the auditor?

- A. Have another auditor review the security architecture.
- B. Disclose the independence issues in the audit report.
- C. Change the audit scope to exclude security architecture.
- D. Postpone the post-implementation audit to a later date.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 132

Of the following, who should authorize a project management team's request to take a mission-critical application offline to implement a new release and configuration?

- A. Chief information security officer (CISO)
- B. Project manager
- C. Application administrator
- D. Business process owner

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 133

An IS auditor is asked to provide feedback on the systems options analysis for a new project. The BEST course of action for the IS auditor would be to:

- A. identify the best alternative.
- B. request at least one other alternative.
- C. comment on the criteria used to assess the alternatives.
- D. retain comments as findings for the audit report.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 134

An IS audit had identified that default passwords for a newly implemented application were not changed. During the follow-up audit, which of the following would provide the BEST evidence that the finding was effectively addressed?

- A. Written confirmation from management that the passwords were changed
- B. Screenshots of system parameters requiring password changes on next login
- C. Application log files that record the password changes
- D. System-generated emails requiring application users to change passwords

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 135

Which of the following is the PRIMARY function of technology-driven enterprise architecture?

- A. To provide guidance on technological decisions in the context of business strategy

- B. To determine how new technologies fit into existing networks and data flows
- C. To help develop project documentation and related business process roadmaps
- D. To re-engineer business processes to make better use of technology

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 136

Which of the following helps to ensure the integrity of data for an interface between a new billing system and an accounts receivable system?

- A. Audit logs are available for 30 days.
- B. Access to the data requires authentication.
- C. Data files are encrypted during transmission.
- D. Control totals are calculated.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 137

The results of a feasibility study for acquiring a new system should provide management with a clear understanding of:

- A. the approach to meeting data processing needs.
- B. how hardware selection criteria are aligned with the IS strategic plan.
- C. critical application systems' utilization of computer resources.
- D. application security over critical data processing.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 138

A configuration management audit identified that predefined automated procedures are used when deploying and configuring application infrastructure in a cloud-based environment. Which of the following is MOST important for the IS auditor to review?

- A. Contracts of vendors responsible for maintaining provisioning tools
- B. Processes for making changes to cloud environment specifications
- C. Storage location of configuration management documentation
- D. Number of administrators with access to cloud management consoles

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 139

Which of the following is the PRIMARY objective of using a capability maturity model as a tool to communicate audit results to senior management?

- A. To evaluate management's action plan
- B. To confirm audit findings
- C. To illustrate improvement opportunities
- D. To prioritize remediation efforts

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 140

Which of the following is the GREATEST advantage of implementing an IT enterprise architecture framework within an organization?

- A. It helps to identify security issues in systems across the organization.
- B. It better equips an organization to adopt innovative and emerging technologies.
- C. It reduces the overlap of infrastructure technologies within the organization.
- D. It improves the organization's ability to meet service level agreements (SLAs).

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 141

When an organization outsources a payroll system to a cloud service provider, the IS auditor's PRIMARY concern should be the:

- A. service level agreement (SLA) is not reviewed annually.
- B. lack of independent assurance from a third party.
- C. service provider's data center is on the ground floor.

D. service provider's platform is not compatible with legacy systems.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 142

The IS security group is planning to implement single sign-on. What is the IS auditor's PRIMARY concern?

- A. Integrated access rules will increase users' access privileges.
- B. Managing user IDs/passwords will require increased efforts.
- C. Integrated access rules will restrict users' access privileges.
- D. Compromise of a user ID/password will yield more privileges.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 143

Which of the following would BEST help in classifying an organization's data?

- A. Data retention requirements
- B. Impact of data loss or disclosure
- C. Analysis of existing data handling procedures
- D. Industry best practices for data classification

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 144

Which of the following should be of GREATEST concern to an organization's board when reviewing the internal audit department's quality assurance and improvement program?

- A. The program does not include periodic external assessments.
- B. Program metrics have not been updated in over two years.
- C. The program has not been approved by senior management.
- D. The program does not incorporate recommendations from prior audits.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 145

Which of the following should be a PRIMARY control objective when designing controls for system interfaces?

- A. Ensure peer-to-peer data transfers are minimized.
- B. Ensure all data transferred through system interfaces is encrypted.
- C. Ensure managed file transfer (MFT) systems have restart capability for interruptions.
- D. Ensure data on the sending system is identical to the data on the receiving system.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 146

Audit software designed to detect invalid data, extreme values, or linear correlations between data elements can be classified as which type of data analytics tool?

- A. Descriptive
- B. Diagnostic
- C. Predictive
- D. Prescriptive

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 147

Which of the following factors constitutes a strength in regard to the use of a disaster recovery planning reciprocal agreement?

- A. Changes to the hardware or software environment by one company could make the agreement ineffective or obsolete.
- B. Reciprocal agreements may not be formally established in a contract.
- C. The two companies might share a need for a specialized piece of equipment.
- D. A disaster could occur that would affect both companies.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 148

Which of the following is the MOST important consideration when establishing vulnerability scanning on critical IT infrastructure?

- A. The scanning will not degrade system performance.
- B. The scanning will be followed by penetration testing.
- C. The scanning will be cost-effective.
- D. The scanning will be performed during non-peak hours.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 149

Which of the following is MOST important for an organization to review before sharing data with an external business partner via an application programming interface (API)?

- A. The business partner's web application log files
- B. The business partner's help desk incident tickets
- C. The business partner's security practices
- D. The business partner's data center access logs

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 150

An organization recently decided to send the backup of its customer relationship management (CRM) system to its cloud provider for recovery. Which of the following should be of GREATEST concern to an IS auditor reviewing this process?

- A. Backups are sent and stored in unencrypted format.
- B. Validation of backup data has not been performed.
- C. The cloud provider is located in a different country.
- D. Testing of restore data has not been performed.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 151

An IS auditor previously worked in an organization's IT department and was involved with the design of the business continuity plan (BCP). The IS auditor has now been asked to review this same BCP. The auditor should FIRST:

- A. document the conflict in the audit report.
- B. decline the audit assignment.
- C. communicate the conflict of interest to the audit manager prior to starting the assignment.
- D. communicate the conflict of interest to the audit committee prior to starting the assignment.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 152

A request for proposal (RFP) for the acquisition of computer hardware should include:

- A. the requirement that the supplier allow a right of audit.
- B. maximum cost restriction.
- C. support and maintenance requirements.
- D. detailed specification of the current hardware infrastructure.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 153

Which of the following would BEST enable an organization to address the security risks associated with a recently implemented bring your own device (BYOD) strategy?

- A. Mobile device upgrade program
- B. Mobile device tracking program
- C. Mobile device awareness program

D. Mobile device testing program

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 154

An IT strategic plan that BEST leverages IT in achieving organizational goals will include:

- A. a risk-based ranking of projects.
- B. a comparison of future needs against current capabilities.
- C. IT budgets linked to the organization's budget.
- D. enterprise architecture impacts.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 155

A disaster recovery plan (DRP) should include steps for:

- A. assessing and quantifying risk.
- B. negotiating contracts with disaster planning consultants.
- C. obtaining replacement supplies.
- D. identifying application control requirements.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 156

In a RACI model, which of the following roles must be assigned to only one individual?

- A. Responsible
- B. Informed
- C. Consulted
- D. Accountable

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 157

A manufacturing company is implementing application software for its sales and distribution system. Which of the following is the MOST important reason for the company choose a centralized online database?

- A. Enhanced data redundancy
- B. Elimination of multiple points of failure
- C. Elimination of the need for data normalization
- D. Enhanced integrity controls

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 158

An organization has replaced all of the storage devices at its primary data center with new, higher capacity units. The replaced devices have been installed at the disaster recovery site to replace older units. An IS auditor's PRIMARY concern would be whether:

- A. the procurement was in accordance with corporate policies and procedures
- B. the relocation plan has been communicated to all concerned parties
- C. a hardware maintenance contract is in place for both old and new storage devices
- D. the recovery site devices can handle the storage requirements

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 159

Which of the following BEST describes a common risk in implementing a new application software package?

- A. Parameter settings are incorrect
- B. Transaction volume is excessive
- C. Sensitivity of transactions is high
- D. The application lacks audit trails

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 160

An organization is replacing a mission-critical system. Which of the following is the BEST implementation strategy to mitigate and reduce the risk of system failure?

- A. Stage
- B. Phase
- C. Parallel
- D. Big-bang

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 161

A month after a company purchased and implemented system and performance monitoring software, reports were too large and therefore were not reviewed or acted upon. The MOST effective plan of action would be to:

- A. use analytical tools to produce exception reports from the system and performance monitoring software
- B. re-install the system and performance monitoring software
- C. evaluate replacement systems and performance monitoring software
- D. restrict functionality of system monitoring software to security-related events

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 162

The PRIMARY objective of conducting a post-implementation review is to:

- A. determine if project management methodology was applied consistently
- B. verify that the information system meets the intended objectives
- C. determine if testing documentation was sufficient
- D. allow employees to provide feedback on the information system

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 163

The MOST significant reason for using key performance indicators (KPIs) to track the progress of IT projects against initial targets is that they:

- A. influence management decisions to outsource IT projects
- B. identify which projects may require additional funding
- C. provide timely indication of when corrective actions need to be taken
- D. identify instances where increased stakeholder engagement is required

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 164

An organization has implemented an automated match between purchase orders, goods receipts, and invoices. Which of the following risks will this control BEST mitigate?

- A. Customer discounts not being applied
- B. A legitimate transaction being paid multiple times
- C. Invalid payments being processed by the system
- D. Delay of purchase orders

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 165

When implementing an upgraded enterprise resource planning (ERP) system, which of the following is the MOST important consideration for a go-live decision?

- A. Test cases
- B. Rollback strategy
- C. Business case
- D. Post-implementation review objectives

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 166

A multinational organization is integrating its existing payroll system with a human resource information system. Which of the following should be of GREATEST concern to the IS auditor?

- A. System documentation
- B. Currency conversion
- C. Application interfaces
- D. Scope creep

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 167

An online retailer is receiving customer about receiving different items from what they ordered on the organization's website. The root cause has been traced to poor data quality. Despite efforts to clean erroneous data from the system, multiple data quality issues continue to occur. Which of the following recommendations would be the BEST way to reduce the likelihood of future occurrences?

- A. Implement business rules to validate employee data entry.
- B. Invest in additional employee training for data entry.
- C. Assign responsibility for improving data quality.
- D. Outsource data cleansing activities to reliable third parties.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 168

When determining whether a project in the design phase will meet organizational objectives, what is BEST to compare against the business case?

- A. Project plan
- B. Requirements analysis
- C. Implementation plan
- D. Project budget provisions

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 169

What would be an IS auditor's BEST recommendation upon finding that a third-party IT service provider hosts the organization's human resources (HR) system in a foreign country?

- A. Conduct a privacy impact analysis.
- B. Implement change management review.
- C. Review third-party audit reports.
- D. Perform background verification checks.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 170

The success of an IT projects is measured PRIMARILY by the:

- A. translation of business vision to function vision
- B. implementation of current technology
- C. benefit that the business derives from the outcome
- D. efficient use of resources

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 171

Which of the following are the PRIMARY considerations when determining the timing of remediation testing?

- A. The level of management and business commitment to implementing agreed action plans
- B. The difficulty of scheduling resources and availability of management for a follow-up engagement
- C. The availability and competencies of control owners for implementing the agreed action
- D. The significance of the reported findings and the impact if corrective actions are not taken

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 172

Code changes are compiled and placed in a change folder by the developer. An implementation team migrates changes to production from the change folder. Which of the following BEST indicates separation of duties is in place during the migration process?

- A. A second individual performs code review before the change is released to production.
- B. The developer approves changes prior to moving them to the change folder.
- C. The implementation team does not have experience writing code.
- D. The implementation team does not have access to change the source code.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 173

Which of the following is a prerequisite to help ensure that IS hardware and software support the delivery of mission-critical functions?

- A. Control over IS infrastructure expenditure
- B. An independent audit of the process
- C. A comprehensive IS applications architecture
- D. Documented emergency change procedures

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 174

Which of the following is the BEST way to control the concurrent use of licensed software?

- A. User self-discipline.
- B. Monitor by system administrator.
- C. Surprise audit conducted by vendors.
- D. Metering software

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 175

When determining the specifications for a server supporting an online application using more than a hundred endpoints, which of the following is the MOST important factor to be considered?

- A. High availability of different systems
- B. Cost-benefit comparison between the available systems
- C. Reputation of the vendors and their customer base
- D. Transaction volume estimate during peak periods

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 176

Following an unauthorized disclosure of data, an organization needs to implement data loss prevention (DLP) measures. The IS auditor's BEST recommendation should be to:

- A. install DLP software on corporate servers to prevent recurrence.
- B. monitor and block outgoing emails based on common DLP criteria.
- C. restrict removable media access on all computer systems.
- D. establish a risk and control framework.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 177

Which of the following is the BEST time for an IS auditor to perform a post-implementation review?

- A. When the system has stabilized.
- B. After the completion of user testing.
- C. Before decommissioning the legacy system.
- D. Immediately after the new system goes into production.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 178

Which of the following is the MOST effective mechanism for ensuring that critical IT operational problems are reported to executive management in a timely manner?

- A. Regular meetings
- B. Escalation procedures
- C. Service level monitoring
- D. Periodic status reports

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 179

What is the PRIMARY advantage of prototyping as part of systems development?

- A. Maximizes user satisfaction
- B. Eliminates the need for internal controls
- C. Increases accuracy in reporting
- D. Reduces the need for compliance testing

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 180

Which of the following is MOST important to consider when creating audit follow-up procedures?

- A. Whether the organization has sufficient funds to address the issue
- B. Whether management has determined if risk is within the organization's risk appetite
- C. Whether follow-up procedures would determine if identified risks have been mitigated
- D. Whether the auditee has allotted sufficient time for the follow-up

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 181

During the procurement process, which of the following would be the BEST indication that prospective vendors will meet the organization's needs?

- A. An account transition manager has been identified.
- B. Expected service levels are defined.
- C. The vendor's subcontractors have been identified.
- D. The service catalog is documented.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 182

When conducting a requirements analysis for a project the BEST approach would be to:

- A. conduct a control self-assessment.
- B. consult key stakeholders.
- C. test operational deliverables.
- D. prototype the requirements.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 183

What is the BEST population to select from when testing that programs are migrated to production with proper approval?

- A. List of changes provided by application programming managers
- B. List of production programs
- C. Completed change request forms
- D. Change advisory board meeting minutes

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Acquisition, Development and Implementation

QUESTION 184

Which of the following is the BEST guidance from an IS auditor to an organization planning an initiative to improve the effectiveness of its IT processes?

- A. IT staff should be surveyed to identify current IT process weaknesses and suggest improvements.
- B. The organization should use a capability maturity model to identify current maturity levels for each IT process.
- C. IT management should include process improvements in staff performance
- D. The organization should refer to prior audit reports to identify the specific IT processes to be improved.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 185

An organization implements a data loss prevention tool as a control to mitigate the risk of sensitive data leaving the organization via electronic mail. Which of the following would provide the BEST indication of adequate control design?

- A. Management has formally approved the control design.
- B. Management presents evidence that data loss incidents have decreased.
- C. Security administrators can demonstrate the functions of the tool.
- D. Rules enforced by the tool were based on the classification of the data.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 186

Which of the following should be the PRIMARY consideration when developing an IT strategy?

- A. IT key performance indicators based on business objectives
- B. Alignment with overall business objectives
- C. Alignment with the IT investment portfolio
- D. Short and long-term plans for the enterprise IT architecture

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 187

An IS auditor is involved in the user testing phase of a development project. The developers wish to use a copy of a peak volume transaction file from the production process to show that the development can cope with the required volume. What is the auditor's PRIMARY concern?

- A. Sensitive production data may be read by unauthorized persons.
- B. The error-handling and credibility checks may not be fully proven.
- C. Users may not wish for production data to be made available for testing.
- D. All functionality of the new process may not be tested.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 188

A post-implementation review of a system implementation has identified that the defined objectives were changed several times without the approval of the project board. What should the IS auditor do NEXT?

- A. Notify the project sponsor and request that the project be reopened.
- B. Ask management to obtain retrospective approvals.
- C. Notify the project management office and raise a finding.
- D. Determine whether the revised objectives are appropriate.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 189

An organization has implemented data storage hardware. Which of the following should an IS auditor review to assess if IT is maximizing storage and network utilization?

- A. Capacity management plans
- B. Downtime statistics
- C. The quality management systems
- D. Routine and non-routine job schedules

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 190

Which of the following is MOST likely to be included in a post-implementation review?

- A. Results of live processing
- B. Current sets of test data
- C. Test results
- D. Development methodology

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 191

At what point in software development should the user acceptance test plan be prepared?

- A. Implementation planning
- B. Requirements definition
- C. Transfer into production
- D. Feasibility study

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 192

At a project steering committee meeting, it is stated that adding controls to business processes undergoing re- engineering is an unnecessary cost. The IS auditor's BEST response is that the actual control overhead for a business process is:

- A. usually considerable, but the benefits of good controls always exceed the cost.
- B. the responsibility of the project manager, and the cost should have been included in the budget.
- C. usually difficult to ascertain but is justifiable, because controls are essential to doing business
- D. usually less than the potential cost of failure caused by lack of controls.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 193

In a decentralized organization, the selection and purchase of IS products is acceptable as long as which of the following conditions exists?

- A. The same operating system is used throughout the organization.
- B. Various offices are independent and exchange data on an occasional basis.
- C. Acquired items are consistent with the organization's short- and long-term IS strategy plans.
- D. Managers undertake a full cost-benefit analysis before deciding what to purchase.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 194

An IS auditor has been asked to audit the proposed acquisition of new computer hardware. The auditor's PRIMARY concern is that:

- A. the implementation plan meets user requirements.
- B. a clear business case has been established.
- C. the new hardware meets established security standards.
- D. a full, visible audit trail will be included.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 195

An effective implementation of security roles and responsibilities is BEST evidenced across an enterprise when:

- A. operational activities are aligned with policies.
- B. policies are signed off by users.
- C. policies are rolled out and disseminated.
- D. reviews and updates of policies are regularly performed.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 196

When evaluating the recent implementation of an intrusion detection system (IDS), an IS auditor should be MOST concerned with inappropriate:

- A. encryption.
- B. training.
- C. tuning.
- D. patching.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 197

A technology service organization has recently acquired a new subsidiary. What should be the IS auditor's NEXT course of action when considering the impact on the development of the IT audit plan?

- A. Review the revised business impact analysis (BIA).
- B. Proceed with the current audit plan.
- C. Perform a risk assessment.
- D. Include the new systems in the audit plan.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 198

During a software acquisition review, an IS auditor should recommend that there be a software escrow agreement when:

- A. the estimated life for the product is less than 3 years.
- B. the deliverables do not include the source code.
- C. the product is new in the market.
- D. there is no service level agreement (SLA).

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 199

Which of the following procedures should be implemented prior to disposing of surplus computer equipment to employees?

- A. Use operating system commands to delete all files from the hard drive.
- B. Have the employee receiving the machine sign a nondisclosure agreement.
- C. Use application delete commands to remove files.
- D. Overwrite the hard drive with random data.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 200

Which of the following controls should be implemented to BEST minimize system downtime for maintenance?

- A. Nightly full backups
- B. Virtualization
- C. Warm site
- D. Clustering

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 201

Implementing which of the following would BEST address issues relating to the aging of IT systems?

- A. IT project management
- B. Release management
- C. Application portfolio management
- D. Configuration management

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 202

The MOST efficient way to confirm that an ERP system being implemented satisfies business expectations is to utilize which of the following types of testing?

- A. Parallel

- B. Pilot
- C. Sociability
- D. Alpha

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 203

An organization has implemented a distributed security administration system to replace the previous centralized one. The IS auditor's GREATEST concern should be that:

- A. security procedures may be inadequate to support the change.
- B. end-user acceptance of the new system is likely to be difficult to obtain.
- C. the new system will require additional training.
- D. a distributed security system is inherently a weak security system.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 204

Which of the following is the BEST indication of the completeness of interface control documents used for the development of a new application?

- A. All documents have been reviewed by end users.
- B. All inputs and outputs for potential actions are included.
- C. Failed interface data transfers prevent subsequent processes.
- D. Both successful and failed interface data transfers are recorded.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 205

An IS auditor identified hard-coded credentials within the source code of recently developed software when evaluating its readiness for implementation. Which of the following would be the auditor's BEST recommendation?

- A. Ensure source code reviews and debugging are performed and documented.
- B. Ensure revisions of source code can be tracked and rollback can be performed.
- C. Ensure documented evidence of source code being kept in escrow is retained.
- D. Ensure log reports are retained of all persons updating software source code.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 206

Assurance tasks required to support security accreditation/certification should be identified:

- A. during the project planning stage.
- B. after necessary modifications are completed.
- C. during the user acceptance phase.
- D. after the quality-assurance plan development.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 207

During an audit in a small organization, an IS auditor finds that some developers have access to migrate changes to the production environment. Which of the following should the auditor do NEXT?

- A. Review change logs for segregation of duties.
- B. Verify whether compensating controls exist.
- C. Advise immediate removal of developer access to production.
- D. Review the information security policy.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 208

What is the PRIMARY reason for conducting a risk assessment when developing an annual IS audit plan?

- A. Identify and prioritize audit areas

- B. Determine the existence of controls in audit areas
- C. Provide assurance material items will be covered
- D. Decide which audit procedures and techniques to use

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 209

An IS auditor is preparing a data set for a data analytics project. The data will be used to benchmark a new computer-assisted audit technique (CAAT) tool being developed. Which of the following will help to ensure the data cannot be identified?

- A. Data masking
- B. Encryption
- C. Anonymization
- D. Data redaction

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 210

Which of the following is MOST important to have in place before developing a disaster recovery plan (DRP)?

- A. A duplicate processing facility
- B. Defined acceptable downtime
- C. Appropriate insurance coverage
- D. System restoration procedures

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 211

Which of the following should be of MOST concern to an IS auditor reviewing the information systems acquisition, development, and implementation process?

- A. Data owners are not trained on the use of data conversion tools.
- B. There is no process for post-implementation approval of emergency changes.
- C. System deployment is routinely performed by contractors.
- D. There is no system documentation available for review.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 212

During which process is regression testing MOST commonly used?

- A. Stress testing
- B. Program development
- C. System modification
- D. Unit testing

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 213

A startup company is considering the use of a cloud service provider to obtain additional computing power needed for software development and testing. Which of the following service models is MOST appropriate in this situation?

- A. Database as a Service (DBaaS)
- B. Software as a Service (SaaS)
- C. Storage as a Service (STaaS)
- D. Platform as a Service (PaaS)

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 214

An organization is planning to develop a system using rapid application development (RAD) in order to meet quick turnaround times. Which of the following is the GREATEST potential risk associated with this type of application development?

- A. Users may be unavailable to contribute.

- B. Costs could spiral out of control.
- C. User requirements may not be met.
- D. The project deadline could be delayed.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 215

For an organization that has plans to implement web-based trading, it would be MOST important for an IS auditor to verify the organization's information security plan includes:

- A. security training prior to implementation.
- B. security requirements for the new application.
- C. attributes for system passwords.
- D. the firewall configuration for the web server.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 216

Which of the following risk management activities is MOST important to complete before implementing an enterprise resource planning (ERP) system?

- A. Optimize business process designs.
- B. Validate compliance with applicable local financial regulations.
- C. Define the organization's control objectives.
- D. Appoint an independent risk advisory firm to provide support.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 217

An organization has contracted with a third party to implement and configure a new accounting application. Once the application is implemented, in-house staff will provide all application support and maintenance. Which of the following is MOST important to the success of this initiative?

- A. Documenting an implementation plan
- B. Establishing a knowledge transfer plan
- C. Conducting a post-implementation review
- D. Ensuring the third party completed testing

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 218

When participating as a member of a system development team, the IS auditor should be aware that:

- A. as a control specialist, the auditor can provide significant value to the project team by making the final decision on specific controls.
- B. the auditor's ability to perform an independent evaluation of the application after implementation will be impaired.
- C. for ongoing evaluation capability, the auditor should ensure that computer audit software is implemented in all applications.
- D. the auditor should sign a statement of independence prior to participating in the project team.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 219

Who is PRIMARILY responsible for data integrity and security when implementing a new application?

- A. Application end users
- B. Project manager
- C. Data custodian
- D. Data owner

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 220

Which of the following would MOST likely lead an organization to consider implementing an IT quality assurance (QA) program?

- A. Decrease in stakeholder satisfaction with IT projects
- B. Increase in the use of non-standard IT infrastructure

- C. Increase in cyber intrusions across the organization
- D. Overspend of IT budgets in various IT projects

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 221

Management has requested a post-implementation review of a newly implemented purchasing package to determine to what extent business requirements are being met. Which of the following is MOST likely to be assessed?

- A. Results of live processing
- B. Test results
- C. Purchasing guidelines and policies
- D. Implementation methodology

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 222

An organization's only IS auditor is asked to design controls for a new system and is also scheduled to audit the system after implementation. Which of the following is the BEST action for the auditor?

- A. Decline to undertake the design role because of the conflict of interest.
- B. Respond positively to the request because there is no conflict of interest.
- C. Request external audit to perform an independent review of the advice to be provided.
- D. Inform the audit committee of the conflict of interest.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 223

Which of the following is the BEST indicator that executive management monitors the implementation of the IT strategy?

- A. IT topics are regular items on the executive committee agenda
- B. IS audit is required to audit large IT investments
- C. Executive management subscribes to IT industry publications
- D. Executive management receives reports on IT resource usage

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 224

Following the last external review, the audit client implemented an advanced data storage solution. Which of the following is MOST important in the audit scope?

- A. Reviewing the implemented storage options and architectures for critical applications
- B. Reviewing procedures to ensure administrators are managing data storage appropriately
- C. Determining whether management has adequate off-site storage of operational procedures and manuals
- D. Ensuring management has completed a cost-benefit analysis and documented results

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 225

During a pre-implementation system review, an IS auditor notes that several identified defects will not be fixed prior to go-live. Which of the following is the auditor's BEST course of action?

- A. Determine which developer's code is responsible for each defect.
- B. Recommend the system does not go live.
- C. Recommend staff augmentation after implementation.
- D. Evaluate the workarounds in place.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 226

Which of the following is the MOST effective control to mitigate against the risk of inappropriate activity by employees?

- A. Network segmentation
- B. User activity monitoring

- C. Access recertification
- D. Two-factor authentication

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 227
Coding standards provide which of the following?

- A. Access control tables
- B. Field naming conventions
- C. Data flow diagrams
- D. Program documentation

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 228
A white box testing method is applicable with which of the following testing processes?

- A. User acceptance testing
- B. Sociability testing
- C. Parallel testing
- D. Integration testing

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 229
Which of the following may be adversely affected when thin client architecture is introduced?

- A. Multi-tenancy
- B. Portability
- C. Availability
- D. Concurrency

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 230
The MOST appropriate control to ensure that all orders transmitted from remote locations to the production department are received accurately would be to:

- A. have data transmitted back to the local site for comparison.
- B. verify that parity checking is still active.
- C. send and reconcile transaction counts and totals.
- D. track and account for the numerical sequence of sales orders.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 231
An IS auditor who was instrumental in designing an application is called upon to review the application. The auditor should:

- A. inform audit management of the earlier involvement.
- B. modify the scope of the audit.
- C. refuse the assignment to avoid conflict of interest.
- D. use the knowledge of the application to carry out the audit.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 232
Which of the following is the GREATEST risk associated with end-user computing used in financial statement reporting?

- A. Inability of IT to support the application
- B. Loss of operational efficiency
- C. Loss of data integrity
- D. Inability to implement segregation of duties

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 233

An organization has decided to implement a third-party system in its existing IT environment. Which of the following is MOST important for the IS auditor to confirm?

- A. The organization has created a clone of the third party's IT infrastructure to host the IT system .
- B. The organization has analyzed the IT infrastructure to determine the feasibility of hosting the IT system.
- C. The organization has maintained a clone of the existing infrastructure as backup.
- D. The organization has purchased a newly released IT infrastructure environment relevant to the IT system .

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 234

Which of the following would be an appropriate role of internal audit in helping to establish an organization's privacy program?

- A. Analyzing risks posed by new regulations
- B. Defining roles within the organization related to privacy
- C. Developing procedures to monitor the use of personal data
- D. Designing controls to protect personal data

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 235

Which of the following provides the MOST assurance over the completeness and accuracy of loan application processing with respect to the implementation of a new system?

- A. Loading balance and transaction data to the new system
- B. Comparing code between old and new systems
- C. Reviewing quality assurance (QA) procedures
- D. Running historical transactions through the new system

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 236

Which of the following MUST be completed before selecting and deploying a biometric system that uses facial recognition software?

- A. Image interference review
- B. Vulnerability assessment
- C. Privacy impact analysis
- D. False acceptance testing

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation [https://csbweb01.uncw.edu/people/ivancevichd/classes/MSA%20516/Extra%20Readings%20on%20Topics/ Access%20Controls/IS%20Audit%20Guidelines%20Biometrics.pdf](https://csbweb01.uncw.edu/people/ivancevichd/classes/MSA%20516/Extra%20Readings%20on%20Topics/Access%20Controls/IS%20Audit%20Guidelines%20Biometrics.pdf)

QUESTION 237

An IS auditor is reviewing the implementation of an international quality management standard. Which of the following provides the BEST evidence that quality management objectives have been achieved?

- A. Reduction in risk profile
- B. Quality assurance (QA) documentation
- C. Measurable processes
- D. Enhanced compliance with laws and regulations

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 238

Which of the following should be done FIRST when planning a penetration test?

- A. Determine reporting requirements for vulnerabilities.
- B. Define the testing scope.
- C. Obtain management consent for the testing.
- D. Execute nondisclosure agreements (NDAs) .

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 239

Which of the following is the MOST likely to ensure that an organization's systems development meets its business objectives?

- A. A focus on strategic projects
- B. Segregation of systems development and testing
- C. Business owner involvement
- D. A project plan with clearly identified requirements

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 240

An incorrect version of source code was amended by a development team. This MOST likely indicates a weakness in:

- A. project management.
- B. quality assurance (QA).
- C. change management.
- D. incident management.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 241

Which of the following is MOST important to verify when implementing an organization's information security program?

- A. The IT department has developed and implemented training programs.
- B. The security program is adequately funded in the budget.
- C. The organization's security strategy is documented and approved.
- D. The security program has been benchmarked to industry standards.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 242

The results of an IS audit indicating the need to strengthen controls has been communicated to the appropriate stakeholders. Which of the following is the BEST way for management to enforce implementation of the recommendations?

- A. Copy senior management on communications related to the audit
- B. Have stakeholders develop a business case for control changes
- C. Assign ownership to each remediation activity
- D. Request auditors to design a roadmap for closure

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 243

During the design phase of a software development project, the PRIMARY responsibility of an IS auditor is to evaluate the:

- A. proposed functionality of the application.
- B. development methodology employed.
- C. future compatibility of the design.
- D. controls incorporated into the system specifications.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Acquisition, Development and Implementation

QUESTION 244

Which of the following is a challenge in developing a service level agreement (SLA) for network services?

- A. Reducing the number of entry points into the network
- B. Ensuring that network components are not modified by the client
- C. Establishing a well-designed framework for network services
- D. Finding performance metrics that can be measured properly

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 245

Which of the following is the MOST appropriate role for an IS auditor assigned as a team member for a software development project?

- A. Implementing controls within the software
- B. Performing a mid-team evaluation of the project management process
- C. Monitoring assessed risk for the project
- D. Developing user acceptance testing (UAT) scripts

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 246

The IS auditor has recommended that management test a new system before using it in production mode. The BEST approach for management in developing a test plan is to use processing parameters that are:

- A. randomly selected by a test generator
- B. simulated by production entities and customers
- C. provided by the vendor of the application
- D. randomly selected by the user

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 247

An IS auditor assessing the controls within a newly implemented call center would FIRST:

- A. review the manual and automated controls in the call center
- B. test the technical infrastructure at the call center
- C. evaluate the operational risk associated with the call center
- D. gather information from the customers regarding response times and quality of service

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 248

A small financial institution is preparing to implement a check image processing system to support planned mobile banking product offerings. Which of the following is MOST critical to the successful implementation of the system?

- A. Feasibility studies
- B. Control design
- C. Integration testing
- D. End user training

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 249

During a project meeting for the implementation of an enterprise resource planning (ERP), a new requirement is requested by the finance department. Which of the following would BEST indicate to an IS auditor that the resulting risk to the project has been assessed?

- A. The analysis of the cost and time impact of the requirement
- B. The updated business requirements
- C. The project status as reported in the meeting minutes
- D. The approval of the change by the finance department

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 250

An organization has recently implemented a Voice-over IP (VoIP) communication system. Which of the following should be the IS auditor's PRIMARY concern?

- A. Lack of integration of voice and data communications
- B. A single point of failure for both voice and data communications
- C. Voice quality degradation due to packet loss
- D. Inability to use virtual private networks (VPNs) for internal traffic

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 251

Which of the following would be MOST useful to an organization planning to adopt a public cloud computing model?

- A. Independent control assessment
- B. Audit report prepared by the service provider
- C. Management attestation report
- D. Service level agreement (SLA) performance metrics

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 252

An organization plans to implement a virtualization strategy enabling multiple operating systems on a single host. Which of the following should be the GREATEST concern with this strategy?

- A. Adequate storage space
- B. Complexity of administration
- C. Network bandwidth
- D. Application performance

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 253

An organization considers implementing a system that uses a technology that is not in line with the organization's IT strategy. Which of the following is the BEST justification for deviating from the IT strategy?

- A. The system has a reduced cost of ownership.
- B. The organization has staff familiar with the technology.
- C. The business benefits are achieved even with extra costs.
- D. The system makes use of state-of-the-art technology.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 254

When introducing a maturity model to the IT management process, it is BEST to align the maturity level to a point that reflects which of the following?

- A. Ideal business production level
- B. Minimum cost expenditure level
- C. Maximum risk tolerance level
- D. Industry-standard practice level

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 255

Which of the following methodologies is MOST appropriate to use for developing software with incomplete requirements?

- A. Process-based
- B. Critical chain
- C. Waterfall
- D. Agile

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 256

Which of the following is MOST important to the effective management of an end user-developed application?

- A. Implementing best practice folder structures
- B. Continuous monitoring to facilitate prompt escalation of issues
- C. Assigning risk ratings based on probability and impact
- D. Stress testing the application through use of data outliers

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 257

A development team has designed a new application and incorporated best practices for secure coding. Prior to launch, which of the following is the IS auditor's BEST recommendation to mitigate the associated security risk?

- A. User acceptance testing
- B. Unit testing
- C. Integration testing
- D. Penetration testing

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 258

Which of the following should be reviewed FIRST when assessing the effectiveness of an organization's network security procedures and controls?

- A. Data recovery capability
- B. Inventory of authorized devices
- C. Vulnerability remediation
- D. Malware defenses

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 259

An organization is implementing the use of mobile devices that will connect to sensitive corporate applications. Which of the following is the BEST recommendation to mitigate risk of data leakage?

- A. Remote data wipe
- B. GPS tracking software
- C. Encrypted RFID tags
- D. Data encryption

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 260

The PRIMARY responsibility of a project steering committee is to:

- A. ensure that each project deadline is met
- B. undertake final acceptance of the system for implementation
- C. ensure that systems developed meet business needs
- D. provide day-to-day guidance and oversight

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 261

An organization has recently incorporated robotic process automation. Which of the following would be of GREATEST concern to an IS auditor?

- A. Controls have not been tested
- B. A governance structure has not been implemented
- C. A risk assessment has not been conducted
- D. The adoption rate for the new technology has been low

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 262

Two organizations will share ownership of a new enterprise resource management (ERM) system. To help ensure the successful implementation of the system, it is MOST important to define:

- A. access to data
- B. the governance model
- C. custody of assets
- D. appropriate procedures

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 263

As IS auditor discovers that due to resource constraints, a database administrator (DBA) is responsible for developing and executing changes into the production environment. Which of the following should the auditor do FIRST?

- A. Identify whether any compensating controls exist
- B. Report a potential segregation of duties (SoD) violation
- C. Determine whether another database administrator could make the changes
- D. Ensure a change management process is followed prior to implementation

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 264

An organization plans to receive an automated data feed into its enterprise data warehouse from a third-party service provider. Which of the following would be the BEST way to prevent accepting bad data?

- A. Appoint data quality champions across the organization
- B. Obtain error codes indicating failed data feeds
- C. Purchase data cleansing tools from a reputable vendor
- D. Implement business rules to reject invalid data

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 265

Which of the following is the MOST important control to implement when senior managers use smartphones to access sensitive company information?

- A. Mandatory virtual private network (VPN) connectivity
- B. Centralized device administration
- C. Strong passwords
- D. Anti-malware on the devices

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 266

When implementing a new risk assessment methodology, which of the following is the MOST important requirement?

- A. The methodology must be approved by the chief executive officer.
- B. Risk assessments must be reviewed annually.
- C. Risk assessments must be conducted by certified staff.
- D. The methodology used must be consistent across the organization.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 267

Which of the following is the MOST likely reason an organization would use Platform as a Service (PaaS)?

- A. To operate third-party hosted applications
- B. To install and manage operating systems
- C. To establish a network and security architecture
- D. To develop and integrate its applications

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 268

Which of the following is the BEST approach to reduce unnecessary duplication of compliance activities?

- A. Integrating of assurance efforts
- B. Automation of controls
- C. Standardization of compliance requirements
- D. Documentation of control procedures

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 269

A risk analysis for a new system is being performed. For which of the following is business knowledge MORE important than IT knowledge?

- A. Vulnerability analysis
- B. Cost-benefit analysis
- C. Impact analysis
- D. Balanced scorecard

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 270

Which of the following is the MOST important security consideration when using infrastructure as a Service (IaaS)?

- A. User access management
- B. Compliance with internal standards
- C. Segmentation among guests
- D. Backup and recovery strategy

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 271

Which of the following sites would be MOST appropriate in the case of a very short recovery time objective (RTO)?

- A. Mobile
- B. Redundant
- C. Shared
- D. Warm

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 272

Which of the following would provide the STRONGEST indication that senior management commitment to information security is lacking within an organization?

- A. Inconsistent enforcement of information security policies
- B. A reduction in information security investment
- C. A high of information security risk acceptance
- D. The information security manager reports to the chief risk officer

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 273

Which of the following is the GREATEST risk associated with the lack of an effective data privacy program?

- A. Failure to prevent fraudulent transactions
- B. Inability to manage access to private or sensitive data
- C. Inability to obtain customer confidence
- D. Failure to comply with data-related regulations

Correct Answer: D
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 274

Which of the following would BEST provide an information security manager with sufficient assurance that a service provider complies with organization's information security requirements?

- A. A live demonstration of the third-party supplier's security capabilities
- B. Third-party security control self-assessment results
- C. An independent review report indicating compliance with industry standards
- D. The ability to audit the third-party supplier's IT systems and processes

Correct Answer: C
Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 275

A design company has multiple name and address files for its customers in several of its independent systems. Which of the following is the BEST control to ensure that the customer name and address agree across all files?

- A. Use of hash totals on customer records

- B. Periodic review of each master file by management
- C. Matching of records and review of exception reports
- D. Use of authorized master file change forms

Correct Answer: A
Explanation

Explanation/Reference:
 Section: Information System Acquisition, Development and Implementation

QUESTION 276

An employee who denies accusations of sending inappropriate images to other employees has been discharged. For evidential purposes, the mail database for the discharged employee's computer should be:

- A. deleted as it could subject the organization to further legal liability
- B. impounded by physically removing the disk drive
- C. backed up to the server, where its access can be tightly restricted
- D. copied to write-once, read-many media using the computer's OS tools

Correct Answer: C
Explanation

Explanation/Reference:
 Section: Information System Acquisition, Development and Implementation

QUESTION 277

Which of the following is MOST important for an organization to complete when planning a new marketing platform that targets advertising based on customer behavior?

- A. Data privacy impact assessment
- B. Data quality assessment
- C. Cross-border data transfer assessment
- D. Security vulnerability assessment

Correct Answer: A
Explanation

Explanation/Reference:
 Section: Information System Acquisition, Development and Implementation

QUESTION 278

A company converted its payroll system from an external service to an internal package. Payroll processing in April was run in parallel. To validate the completeness of data after the conversion, which of the following comparisons from the old to the new system would be MOST effective?

- A. Turnaround time for payroll processing
- B. Employee counts and year-to-date payroll totals
- C. Master file employee data to payroll journals
- D. Cut-off dates and overwrites for a sample of employees

Correct Answer: C
Explanation

Explanation/Reference:
 Section: Information System Acquisition, Development and Implementation

QUESTION 279

Which of the following is the client organization's responsibility in a Software as a Service (SaaS) environment?

- A. Detecting unauthorized access
- B. Ensuring that users are properly authorized
- C. Ensuring the data is available when needed
- D. Preventing insertion of malicious code

Correct Answer: B
Explanation

Explanation/Reference:
 Section: Information System Acquisition, Development and Implementation

QUESTION 280

One advantage of monetary unit sampling is the fact that:

- A. results are stated in terms of the frequency of items in error
- B. it can easily be applied manually when computer resources are not available
- C. it increases the likelihood of selecting material items from the population
- D. large-value population items are segregated and audited separately

Correct Answer: A
Explanation

Explanation/Reference:
 Section: Information System Acquisition, Development and Implementation

QUESTION 281

An existing system is being replaced with a new application package. User acceptance testing (UAT) should ensure that:

- A. data from the old system has been converted correctly

- B. the new system functions as expected
- C. the new system is better than the old system
- D. there is a business need for the new system

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 282

An employee of an organization has reported losing a smartphone that contains sensitive information. The BEST step to address this situation should be to:

- A. terminate the device connectivity
- B. escalated to the user's management
- C. disable the user's access to corporate resources
- D. remotely wipe the device

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 283

As part of an international expansion plan, an organization has acquired a company located in another jurisdiction. Which of the following would be the BEST way to maintain an effective information security program?

- A. Determine new factors that could influence the information security strategy.
- B. Implement the current information security program in the acquired company.
- C. Merge the two information security programs to establish continuity.
- D. Ensure information security is included in any change control efforts.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 284

In an organization that has undergone an expansion through an acquisition, which of the following would BEST secure the enterprise network?

- A. Business or role-based segmentation
- B. Using security groups
- C. Log analysis of system access
- D. Encryption of data traversing networks.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 285

Which type of control is being implemented when a biometric access device is installed at the entrance to a facility?

- A. Preventive
- B. Deterrent
- C. Corrective
- D. Detective

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 286

Which of the following is the BEST physical security solution for granting and restricting access to individuals based on their unique access needs?

- A. Bolting door locks
- B. Cipher locks
- C. Closed-circuit television (CCTV)
- D. Electronic badge system

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 287

Which of the following methods should be used to purge confidential data from write-once optical media?

- A. Degauss the media.
- B. Destroy the media.
- C. Remove the references to data from the access index.

D. Write over the data with null values.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 288

Which of the following is the MOST effective way to minimize the risk of a SQL injection attack?

- A. Reconfiguring content filtering settings
- B. Performing activity monitoring
- C. Using secure coding practices
- D. Implementing an intrusion detection tool

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Acquisition, Development and Implementation

QUESTION 289

Which of the following is used in providing logical access control to restrict updating or deleting business information in a relational database?

- A. Trigger
- B. View
- C. Join
- D. Primary key

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 290

Which of the following is the MOST reliable control to prevent double payments made as a result of payment system batch jobs restarting after processing errors?

- A. Database rollback in case of processing errors
- B. Review of batch job completion logs
- C. Duplicate verification at the last possible point in processing
- D. Restart procedures integrated in job controls

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 291

A programmer has made unauthorized changes to key fields in a payroll system report. Which of the following control weaknesses would have contributed MOST to this problem?

- A. The user requirements were not documented.
- B. Payroll files were not under the control of a librarian.
- C. The programmer did not involve the user in testing.
- D. The programmer has access to the production programs.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 292

Which cloud deployment model is MOST likely to be limited in scalability?

- A. Public
- B. Private
- C. Hybrid
- D. Community

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 293

Malicious program code was found in an application and corrected prior to release into production. After the release, the same issue was reported. Which of the following is the IS auditor's BEST recommendation?

- A. Ensure the business signs off on end-to-end user acceptance test results.
- B. Ensure corrected program code is compiled in a dedicated server.
- C. Ensure change management reports are independently reviewed.
- D. Ensure programmers cannot access code after the completion of program edits.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 294

During a computer forensics investigation, what is the PRIMARY reason for obtaining a bit-for-bit copy of data in storage?

- A. To document findings
- B. To obtain residual data
- C. To obtain data as well as source code details
- D. To transfer the data into a controlled location

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 295

Controls related to authorized modifications to production programs are BEST tested by:

- A. testing only the authorizations to implement the new program.
- B. tracing modifications from the executable program back to the original request for change.
- C. reviewing only the actual lines of source code changed in the program.
- D. tracing modifications from the original request for change forward to the executable program.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 296

IS management has decided to replace the current single-server-based local area network (LAN) with three interconnected servers running different operating systems. Existing applications and data on the old server have been exclusively distributed on the new servers. This will MOST likely result in:

- A. disclosure of information.
- B. multiple authentication.
- C. data incompleteness.
- D. data unavailability.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 297

A retailer normally uses a scanner to read product labels and input product codes and prices. The unit is not functioning and staff are keying information manually. With respect to the accuracy of the input, it is likely that:

- A. audit risk has increased.
- B. control risk has increased.
- C. inherent risk has decreased.
- D. detection risk has decreased.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 298

When reviewing an end-user computing (EUC) application, which of the following techniques is MOST appropriate for testing program logic?

- A. Integrated testing facility
- B. Test decking
- C. Re-performance
- D. Key calculation inspection

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 299

Which of the following would provide the MOST assurance that an application will work in a live environment?

- A. Walking through the programs to view the results of error processing
- B. Processing of test data to prove that data can be passed between individual programs
- C. Walking through the programs to view the results of processing copies of production data.
- D. Processing of valid and erroneous data in an acceptance test environment

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 300

For a company that outsources payroll processing, which of the following is the BEST way to ensure that only authorized employees are paid?

- A. The company's bank reconciliations should be independently prepared and checked.
- B. Employees should receive pay statements showing gross pay, net pay, and deductions.
- C. Only payroll employees should be given the password for data entry and report retrieval.
- D. Electronic payroll reports should be independently reviewed.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 301

Which of the following strategies BEST optimizes data storage without compromising data retention practices?

- A. Limiting the size of the file attachments being sent via email
- B. Automatically deleting emails older than one year
- C. Moving emails to a virtual email vault after 30 days
- D. Allowing employees to store large emails on flash drives

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 302

Which of the following provides the MOST reliable audit evidence on the validity of transactions in a financial application?

- A. Substantive testing
- B. Walk-through reviews
- C. Compliance testing
- D. Design documentation reviews

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 303

Which of the following BEST helps to identify errors during data transfer?

- A. Decrease the size of data transfer packets.
- B. Test the integrity of the data transfer.
- C. Review and verify the data transfer sequence numbers.
- D. Enable a logging process for data transfer.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 304

To create a digital signature in a message using asymmetric encryption, it is necessary to:

- A. first use a symmetric algorithm for the authentication sequence.
- B. encrypt the authentication sequence using a public key.
- C. transmit the actual digital signature in unencrypted clear text.
- D. encrypt the authentication sequence using a private key.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 305

What is the PRIMARY benefit of prototyping as a method of system development?

- A. Reduces the need for testing.
- B. Minimizes the time the IS auditor has to review the system.
- C. Increases the likelihood of user satisfaction.
- D. Eliminates the need for documentation.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 306

To ensure confidentiality through the use of asymmetric encryption, a message is encrypted with which of the following?

- A. Sender's private key
- B. Recipient's private key
- C. Sender's public key
- D. Recipient's public key

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 307

Which of the following methods BEST ensures that a comprehensive approach is used to direct information security activities?

- A. Creating communication channels
- B. Promoting security training
- C. Establishing a steering committee
- D. Holding periodic meetings with business owners

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 308

An organization's marketing department has requested access to cloud-based collaboration sites for exchanging media files with external marketing companies. As a result, the information security manager has been asked to perform a risk assessment. Which of the following should be the MOST important consideration?

- A. The information to be exchanged
- B. Methods for transferring the information
- C. Reputations of the external marketing companies
- D. The security of the third-party cloud provider

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 309

Which of the following is the BEST reason for delaying the application of a critical security patch?

- A. Lack of vulnerability management
- B. Conflicts with software development life cycle
- C. Technology interdependencies
- D. Resource limitations

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 310

Which of the following is the MOST important reason to document information security incidents that are reported across the organization?

- A. Prevent incident recurrence.
- B. Support business investments in security.
- C. Identify unmitigated risk.
- D. Evaluate the security posture of the organization.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 311

A message is being sent with a hash. The risk of an attacker changing the message and generating an authentic hash value can be mitigated by:

- A. requiring the recipient to use a different hash algorithm.
- B. generating hash output that is the same size as the original message.
- C. using a secret key in conjunction with the hash algorithm.
- D. using the sender's public key to encrypt the message.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 312

Which of the following is the MOST effective data loss control when connecting a personally owned mobile device to the corporate email system?

- A. A senior manager must approve each new connection.
- B. Email synchronization must be prevented when connected to a public Wi-Fi hotspot.
- C. Email must be stored in an encrypted format on the mobile device.
- D. Users must agree to allow the mobile device to be wiped if it is lost.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 313

A payroll application system accepts individual user sign-on IDs and then connects to its database using a single application ID. The GREATEST weakness under this system architecture is that:

- A. an incident involving unauthorized access to data cannot be tied to a specific user.
- B. when multiple sessions with the same application ID collide, the database locks up.
- C. users can gain direct access to the application ID and circumvent data controls.
- D. the database becomes unavailable if the password of the application ID expires.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 314

Which of the following is the MOST effective mitigation strategy to protect confidential information from insider threats?

- A. Implementing authentication mechanisms
- B. Performing an entitlement review process
- C. Defining segregation of duties
- D. Establishing authorization controls.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 315

A contract bid is digitally signed and electronically mailed. The PRIMARY advantage to using a digital signature is that:

- A. the bid cannot be forged even if the keys are compromised.
- B. the bid and the signature can be copied from one document to another.
- C. the signature can be authenticated even if no encryption is used.
- D. any alteration of the bid will invalidate the signature.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 316

Which of the following functions is MOST critical when initiating the removal of system access for terminated employees?

- A. Legal
- B. Help desk
- C. Human resources
- D. Information security

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 317

Labeling information according to its security classification:

- A. reduces the need to identify baseline controls for each classification.
- B. reduces the number and type of countermeasures required.
- C. enhances the likelihood of people handling information securely.
- D. affects the consequences if information is handled insecurely.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 318

Which of the following MOST effectively prevents internal users from modifying sensitive data?

- A. Network segmentation

- B. Multi-factor authentication
- C. Acceptable use policies
- D. Role-based access controls

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 319

Which of the following is the PRIMARY benefit to an organization using an automated event monitoring solution?

- A. Enhanced forensic analysis
- B. Improved response time to incidents
- C. Improved network protection
- D. Reduced need for manual analysis

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 320

Which of the following would present the GREATEST need to revise information security policies?

- A. An increase in reported incidents
- B. A merger with a competing company
- C. Implementation of a new firewall
- D. Changes in standards and procedures

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 321

When information security management is receiving an increased number of false positive incident reports, which of the following is MOST important to review?

- A. The security awareness programs
- B. Post-incident analysis results
- C. The risk management processes
- D. Firewall logs

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 322

What should the information security manager do FISRT when end users express that new security controls are too restrictive?

- A. Perform a risk assessment on modifying the control environment.
- B. Perform a cost-benefit analysis on modifying the control environment.
- C. Conduct a business impact analysis (BIA).
- D. Obtain process owner buy-in to remove the controls.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 323

Which of the following is the BEST method to defend against social engineering attacks?

- A. Periodically perform antivirus scans to identify malware.
- B. Communicate guidelines to limit information posted to public sites.
- C. Monitor for unauthorized access attempts and failed logins.
- D. Employ the use of a web-content filtering solution.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 324

Which of the following BEST reduces the likelihood of leakage of private information via email?

- A. Strong user authentication protocols
- B. Email encryption
- C. Prohibition on the personal use of email
- D. User awareness training

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 325

Which of the following should be PRIMARILY included in a security training program for business process owners?

- A. Application vulnerabilities
- B. List of security incidents reported
- C. Application recovery time
- D. Impact of security risks

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 326

What is the MOST effective way to ensure information security incidents will be managed effectively and in a timely manner?

- A. Obtain senior management commitment.
- B. Test incident response procedures regularly.
- C. Communicate incident response procedures to staff.
- D. Establish and measure key performance indicators (KPIs).

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 327

During an annual security review of an organization's servers, it was found that the customer service team's file server, which contains sensitive customer data, is accessible to all user IDs in the organization. Which of the following should the information security manager do FIRST?

- A. Report the situation to the data owner.
- B. Remove access privileges to the folder containing the data.
- C. Train the customer service team on properly controlling file permissions.
- D. Isolate the server from the network.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 328

Which of the following is the BEST way to improve the timely reporting of information security incidents?

- A. Perform periodic simulations with the incident response team.
- B. Incorporate security procedures in help desk processes.
- C. Integrate an intrusion detection system (IDS) in the DMZ.
- D. Regularly reassess and update the incident response plan.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 329

Which of the following is the PRIMARY purpose of red team testing?

- A. To determine the organization's preparedness for an attack
- B. To confirm the risk profile of the organization
- C. To assess the vulnerability of employees to social engineering
- D. To establish a baseline incident response program

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 330

The MOST important reason to use a centralized mechanism to identify information security incidents is to:

- A. prevent unauthorized changes to networks.
- B. comply with corporate policies.
- C. detect potential fraud.
- D. detect threats across environments.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 331

When recommending a preventive control against cross-site scripting in web applications, an information security manager is MOST likely to suggest:

- A. using https in place of http.
- B. hardening of the web server's operating system.
- C. consolidating multiple sites into a single portal.
- D. coding standards and code review.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 332

An organization has detected sensitive data leakage caused by an employee of a third-party contractor. What is the BEST course of action to address this issue?

- A. Include security requirements in outsourcing contracts.
- B. Activate the organization's incident response plan.
- C. Limit access to the third-party contractor.
- D. Terminate the agreement with the third-party contractor.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 333

Which of the following external entities would provide the BEST guidance to an organization facing advanced attacks?

- A. Recognized threat intelligence communities
- B. Open-source reconnaissance
- C. Disaster recovery consultants widely endorsed in industry forums
- D. Incident response experts from highly regarded peer organizations

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 334

A validated patch to address a new vulnerability that may affect a mission-critical server has been released. What should be done immediately?

- A. Add mitigating controls.
- B. Check the server's security and install the patch.
- C. Conduct an impact analysis.
- D. Take the server off-line and install the patch.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 335

Which of the following would be an information security manager's PRIMARY challenge when deploying a bring your own device (BYOD) mobile program in an enterprise?

- A. End user acceptance
- B. Mobile application control
- C. Configuration management
- D. Disparate device security

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 336

Which of the following is the MOST significant risk associated with the use of virtualization?

- A. Insufficient network bandwidth
- B. Single point of failure
- C. Inadequate configuration
- D. Performance issues of hosts

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 337

Which of the following is the MOST effective way to verify an organization's ability to continue its essential business operations after a disruption event?

- A. Analysis of end-to-end recovery flow
- B. Analysis of recovery point objectives (RPOs)
- C. Analysis of call tree
- D. Analysis of business impact

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 338

During an IS audit of a data center, it was found that programmers are allowed to make emergency fixes to operational programs. Which of the following should be the IS auditor's PRIMARY recommendation?

- A. Bypass user ID procedures should be put in place to ensure that the changes are subject to after-the-event approval and testing
- B. The ability to undertake emergency fixes should be restricted to selected key personnel
- C. Programmers should be allowed to implement emergency fixes only after obtaining verbal agreement from the application owner
- D. Emergency program changes should be subject to program migration and testing procedures before they are applied to operational systems

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 339

An IS auditor observes that routine backups of operational databases are taking longer than before. Which of the following would MOST effectively help to reduce backup and recovery times for operational databases?

- A. Utilizing database technologies to achieve efficiencies
- B. Using solid storage device (SSD) media
- C. Requiring a combination of weekly full backups and daily differential backups
- D. Archiving historical data in accordance with the data retention policy

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 340

Which of the following is the GREATEST concern associated with control self-assessments?

- A. Employees may have insufficient awareness of controls
- B. Controls may not be assessed objectively
- C. Communication between operational management and senior management may not be effective
- D. The assessment may not provide sufficient assurance to stakeholders

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 341

The BEST test to determine whether an application's internal security controls are configured in compliance with the organization's security standards is an evaluation of the:

- A. availability and frequency of security reports
- B. intrusion detection system (IDS) logs
- C. application's user accounts and passwords
- D. business application's security parameter settings

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 342

Which of the following could provide an organization with the fastest resumption of processing following a disk failure?

- A. Server load balancing
- B. Mirroring
- C. Open database connectivity (ODBC) of the backup server
- D. Replication

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 343

The members of an emergency incident response team should be:

- A. selected from multiple departments
- B. assigned at the time of each incident
- C. restricted to IT personnel
- D. appointed by the CISO

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 344

What is the MOST important role of a Certificate Authority (CA) when a private key becomes compromised?

- A. Issue a new private key to the user
- B. Refresh the key information database in the certificate publishing server
- C. Publish the certificate revocation lists (CRL) into the repository
- D. Refresh the metadata of the certificates

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 345

Which of the following is the BEST way to increase the effectiveness of security incident detection?

- A. Determining containment activities based on the type of incident
- B. Establishing service level agreements (SLAs) with appropriate forensic service providers
- C. Educating end users on identifying suspicious activity
- D. Documenting root cause analysis procedures

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 346

Several remote users have been unable to communicate with a secured network news transfer protocol (NNTP) server. Of the following, the MOST likely cause is:

- A. the use of a password cracker
- B. a hacker impersonating the server
- C. a hacker using a sniffer
- D. a replay attack by an eavesdropper

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 347

Which of the following MOST effectively provides assurance of ongoing service delivery by a vendor?

- A. Regular status reporting provided by the vendor
- B. Short incident response time by the vendor
- C. Pre-defined service and operational level agreements
- D. Regular monitoring by service management team

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 348

Which of the following tests is MOST likely to detect an error in one subroutine resulting from a recent change in another subroutine?

- A. Stress testing
- B. Regression testing
- C. User acceptance testing
- D. Black-box testing

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 349

Reconciliations have identified data discrepancies between an enterprise data warehouse and a revenue system for key financial reports. What is the GREATEST risk to the organization in this situation?

- A. The key financial reports may no longer be produced
- B. Financial reports may be delayed
- C. Undetected fraud may occur
- D. Decisions may be made based on incorrect information

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 350

Which of the following is the MOST important feature of access control software?

- A. Authentication
- B. Violation reporting
- C. Nonrepudiation
- D. Identification

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 351

The BEST access strategy while configuring a firewall would be to:

- A. permit access to all and log the activity
- B. deny access to all but permit selected
- C. permit access to all but deny selected
- D. deny access to all except authorized programs

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 352

For several years, a vendor has been providing offsite backup media and record storage for a bank. Due to familiarity with bank employees, the vendor does not consistently require authorization forms from them to retrieve media. Which of the following is the GREATEST risk from this situation?

- A. Bank employees can inappropriately obtain sensitive records
- B. Backup tapes may not be available
- C. Chain of custody could not be validated
- D. The vendor provides the incorrect media to employees

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 353

Following a successful attack on an organization's web server, which of the following actions should be performed FIRST?

- A. Review the boundary configuration rules to ensure that outbound packets are limited
- B. Evaluate and deploy an intrusion detection system
- C. Periodically scan the network for systems with well-known vulnerabilities
- D. Establish reference systems using cryptographic checksum tools

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 354

Which of the following application input controls would MOST likely detect data input errors in the customer account number field during the processing of an accounts receivable transaction?

- A. Validity check
- B. Reasonableness check
- C. Parity check
- D. Limit check

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 355

A firewall has been installed on the company's web server. Which concern does the firewall address?

- A. Availability of the information
- B. Unauthorized modification of information by internal users
- C. Accessing information by the outside world
- D. Connectivity to the Internet

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 356

An organization is within a jurisdiction where new regulations have recently been announced to restrict cross-border data transfer of personally identifiable information (PII). Which of the following IT decisions will MOST likely need to be assessed in the context of this change?

- A. Hosting the payroll system at an external cloud service provider
- B. Purchasing cyber insurance from an overseas insurance company
- C. Applying encryption to database hosting PII data
- D. Hiring IT consultants from overseas

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 357

A recent audit concluded that an organization's information security system was weak and that monitoring would likely fail to detect penetration. Which of the following would be the MOST appropriate recommendation?

- A. Look continually for new criminal behavior and attacks on sensitive data
- B. Establish a clear policy related to security and the handling of sensitive data
- C. Encrypt sensitive data while strengthening the system
- D. Identify and periodically remove sensitive data that is no longer needed

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 358

A data breach has occurred at a third-party vendor used by an organization to outsource the processing of its customer data. What should be management's FIRST course of action?

- A. Activate the disaster recovery plan
- B. Notify the insurance company of the potential claim
- C. Activate the incident management process
- D. Take legal action against the service provider for reputation damage

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 359

Which of the following should be performed immediately after a computer security incident has been detected and analyzed by an incident response team?

- A. Assess the impact of the incident on critical systems
- B. Categorize the incident
- C. Eradicate the component that caused the incident
- D. Contain the incident before it spreads

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 360

An advantage of installing a thin client architecture in a local area network (LAN) is that this would:

- A. stabilize network bandwidth requirements
- B. facilitate the updating of software versions
- C. ensure application availability when the server is down
- D. reduce the risk of a single point of failure

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 361

During an external assessment of network vulnerability, which of the following activities should be performed FIRST?

- A. Collect network information
- B. Implement an intrusion detection system (IDS)
- C. Monitor the network
- D. Review policies

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 362
Which of the following provides for the GREATEST cost reduction in a large data center?

- A. Server consolidation
- B. Staff rotation
- C. Power conditioning
- D. Job-scheduling software

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 363
Which of the following would BEST prevent data from being orphaned?

- A. Referential integrity
- B. Table partitioning
- C. Input validation checks
- D. Table indexes

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 364
What is the PRIMARY reason for hardening new devices before introducing into a corporate network?

- A. To comply with organizational rules
- B. To ease maintenance of devices
- C. To reduce exposure to attacks
- D. To avoid software licensing conflicts

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 365
Which of the following is the MOST reliable network connection medium in an environment where there is strong electromagnetic interference?

- A. Coaxial cable
- B. Fiber optic cable
- C. Shielded twisted-pair cable
- D. Wireless link

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 366
When consolidating several applications from two outdated servers onto one new server, which of the following is the GREATEST concern?

- A. Increased software licensing cost
- B. Maintenance requires more coordination
- C. Decreased utilization of capacity
- D. Increased network traffic

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 367
During a routine check, a system administrator identifies unusual activity indicating an intruder within a firewall. Which of the following controls has MOST likely been compromised?

- A. Identification
- B. Data integrity

- C. Data validation
- D. Authentication

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 368

Which of the following is MOST important when an incident may lead to prosecution?

- A. Right to perform e-discovery
- B. Adherence to incident response procedures
- C. Advice from legal counsel
- D. Preservation of evidence

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 369

An organization is considering replacing physical backup tapes stored offsite with real-time on-line backup to a storage area network (SAN) located in the primary data center. Which of the following is the GREATEST risk?

- A. Archived data may not satisfy data retention requirements
- B. A single disaster could cause significant data loss
- C. Backups may require excessive storage space
- D. Implementation could cause significant cost increases

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 370

Which of the following is the BEST way to achieve high availability and fault tolerance for an e-business system?

- A. Network diversity
- B. Storage area network
- C. Robust systems architecture
- D. Secure offsite backup storage

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 371

Which of the following procedures would BEST contribute to the reliability of information in a data warehouse?

- A. Retaining only current data
- B. Storing only a single type of data
- C. Maintaining archive data
- D. Maintaining current metadata

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 372

Which of the following is the PRIMARY responsibility of an organization's information security function?

- A. Reviewing unauthorized attempts to access sensitive files
- B. Managing the organization's security procedures
- C. Approving access to data files
- D. Installing network security programs

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 373

During the extraction and transfer process of data from an application database to an enterprise data warehouse, some of the fields were not picked up in the extraction process and therefore did not end up in the data warehouse. Which of the following is the GREATEST concern with this situation?

- A. Costs associated with correcting the process may exceed budget
- B. Transaction errors may occur within the application
- C. Management decisions may be based on incorrect data

D. Management reporting could be delayed

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 374

Which of the following is the MOST important consideration when investigating a security breach of an e-commerce application?

- A. Chain of custody
- B. Skill set of the response team
- C. Notifications to law enforcement
- D. Procedures to analyze evidence

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 375

The risk of communication failure in an e-commerce environment is BEST minimized through the use of:

- A. alternative or diverse routing
- B. compression software to minimize transmission duration
- C. a packet filtering firewall to reroute messages
- D. functional or message acknowledgments

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 376

The operations team of an organization has reported an IS security attack. Which of the following should be the NEXT step for the security incident response team?

- A. Document lessons learned.
- B. Prioritize resources for corrective action.
- C. Perform a damage assessment.
- D. Report results to management.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 377

Which of the following could be used to evaluate the effectiveness of IT operations?

- A. Total cost of ownership
- B. Net present value
- C. Balanced scorecard
- D. Internal rate of return

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 378

The MOST important reason for documenting all aspects of a digital forensic investigation is that documentation:

- A. provides traceability for independent investigation by third parties.
- B. ensures compliance with corporate incident response policies.
- C. ensures the process will be repeatable in future investigations.
- D. meets IT audit documentation standards.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 379

What is the GREATEST concern for an IS auditor reviewing contracts for licensed software that executes a critical business process?

- A. Software escrow was not negotiated.
- B. An operational level agreement (OLA) was not negotiated.
- C. The contract does not contain a right-to-audit clause.
- D. Several vendor deliverables missed the commitment date.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 380

When conducting a follow-up audit on an organization's firewall configuration, the IS auditor discovered that the firewall had been integrated into a new system that provides both firewall and intrusion detection capabilities. The IS auditor should:

- A. consider the follow-up audit unnecessary since the firewall is no longer being used.
- B. assess whether the integrated system addresses the identified risk.
- C. review the compatibility of the new system with existing network controls.
- D. evaluate whether current staff is able to support the new system.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 381

Which of the following would be the MOST effective method to address software license violations on employee workstations?

- A. Restricting administrative rights on employee workstations
- B. Requiring automated installation of software
- C. Scanning of workstations daily for unauthorized software use
- D. Implementing real-time monitoring software on employee workstations

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 382

Which of the following BEST minimizes performance degradation of servers used to authenticate users of an e-commerce website?

- A. Configure each authentication server and ensure that the disks of each server form part of a duplex.
- B. Configure each authentication server as belonging to a cluster of authentication servers.
- C. Configure a single server as a primary authentication server and a second server as a secondary authentication server.
- D. Configure each authentication server and ensure that each disk of its RAID is attached to the primary controller.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 383

Which of the following should be the MOST important consideration when establishing data classification standards?

- A. An education campaign is established upon rollout.
- B. Reporting metrics are established.
- C. Management supports the newly developed standards.
- D. The standards comply with relevant regulations.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 384

The MAJOR reason for segregating test programs from production programs is to:

- A. achieve segregation of duties between IS staff and end users.
- B. limit access rights of IS staff to the development environment.
- C. provide control over program changes.
- D. provide the basis for efficient system change management.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 385

Which of the following entities is BEST suited to define the data classification levels within an organization?

- A. Database administrator (DBA) based on the data schema
- B. Legal compliance team based on the application regulations
- C. Business owner responsible for the respective data
- D. System administrator responsible for data security controls

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 386

An IT organization's incident response plan is which type of control?

- A. Preventive
- B. Corrective
- C. Detective
- D. Directive

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 387

Which of the following is an example of a preventive control in an accounts payable system?

- A. The system only allows payments to vendors who are included in the system's master vendor list.
- B. Policies and procedures are clearly communicated to all members of the accounts payable department.
- C. The system produces daily payment summary reports that staff use to compare against invoice totals.
- D. Backups of the system and its data are performed on a nightly basis and tested periodically.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 388

Which of the following areas of responsibility would cause the GREATEST segregation of duties conflict if the individual who performs the related tasks also has approval authority?

- A. Purchase requisitions and purchase orders
- B. Invoices and reconciliations
- C. Vendor selection and statements of work
- D. Good receipts and payments

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 389

The information security function in a large organization is MOST effective when:

- A. decentralized as close to the user as possible.
- B. the function reports directly to the IS operations manager.
- C. partnered with the IS development team to determine access rights.
- D. established at a corporate-wide level.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 390

Which of the following is MOST helpful in preventing a systems failure from occurring when an application is replaced using the abrupt changeover technique?

- A. Comprehensive documentation
- B. Comprehensive testing
- C. Threat and risk assessment
- D. Change management

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 391

Which of the following would represent an acceptable test of an organization's business continuity plan (BCP)?

- A. Benchmarking the plan against similar organizations
- B. Paper test involving functional areas
- C. Full test of computer operations at an emergency site
- D. Walk-through of the plan with technology suppliers

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 392

Which of the following would be the GREATEST risk associated with a new chat feature on a retailer's website?

- A. Productivity loss
- B. Reputational damage
- C. Data loss
- D. System downtime

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 393

Which of the following is the MOST likely result of the ongoing deterioration of a detective control?

- A. Increased number of data loss events
- B. Increased security incident response time
- C. Decreased effectiveness of root cause analysis
- D. Decreased overall recovery time

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 394

Following the discovery of inaccuracies in a data warehouse, an organization has implemented data profiling, cleansing, and handling filters to enhance the quality of data obtained from connected sources. Which type of control has been applied?

- A. Directive control
- B. Corrective control
- C. Compensating control
- D. Detective control

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 395

Which of the following is the BEST approach for performing a business impact analysis (BIA) of a supply-chain management application?

- A. Circulating questionnaires to key internal stakeholders
- B. Interviewing groups of key stakeholders
- C. Accepting IT personnel's view of business issues
- D. Reviewing the organization's policies and procedures

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 396

Inherent risk ratings are determined by assessing the impact and likelihood of a threat or vulnerability occurring:

- A. after internal controls are taken into account.
- B. before the risk appetite is established.
- C. after compensating controls have been applied.
- D. before internal controls are taken into account.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 397

Which of the following is the BEST type of backup to minimize the associated time and media?

- A. Differential
- B. Incremental
- C. Mirror
- D. Compressed full

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 398

Which of the following BEST provides continuous availability of network bandwidth for critical application services?

- A. Configuration management
- B. Cloud computing
- C. Problem management
- D. Quality of service (QoS)

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 399

During a business process re-engineering (BPR) program, IT can assist with:

- A. total cost of ownership.
- B. focusing on value-added tasks.
- C. segregation of duties.
- D. streamlining of tasks.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 400

Which of the following would be MOST helpful when assessing how applications exchange data with other applications?

- A. List of servers and their applications
- B. Entity relationship diagram
- C. Results of a risk assessment on the applications
- D. Configuration management database

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 401

The objective of using coding standards for systems development is to:

- A. facilitate program maintenance.
- B. facilitate user testing.
- C. ensure the completeness of requirements.
- D. ensure that business needs are met.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 402

Which of the following sampling techniques is commonly used in fraud detection when the expected occurrence rate is small and the specific controls are critical?

- A. Discovery sampling
- B. Monetary unit sampling
- C. Stop-or-go sampling
- D. Random sampling

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 403

The IS auditor of a power company finds that the radio link to a remote mountain site is experiencing systematic outages under specific weather conditions. The communications manager explains that increasing the radio power would require a new license and would help little. What is the MOST appropriate action by the IS auditor?

- A. Recommend that the site's data collection and transmission be non-interruptible.
- B. Review the installation license, permissions and associated costs.
- C. Recommend that the site's hardware be upgraded to record data during outages.
- D. Gather additional information to identify threats, vulnerabilities, and impact.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 404

Which of the following IS audit findings should be of GREATEST concern when preparing to migrate to a new core system using a direct cut-over?

- A. Incomplete test cases for some critical reports

- B. Informal management approval to go live
- C. Lack of a rollback strategy for the system go-live
- D. Plans to use some workarounds for an extended period after go-live

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 405

Which of the following attacks could capture network user passwords?

- A. Data diddling
- B. Sniffing
- C. IP Spoofing
- D. Surfing

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support A network sniffer captures a copy every packet that traverses the network segment the sniffer is connect to. Sniffers are typically devices that can collect information from a communication medium, such as a network. These devices can range from specialized equipment to basic workstations with customized software. A sniffer can collect information about most, if not all, attributes of the communication. The most common method of sniffing is to plug a sniffer into an existing network device like a hub or switch. A hub (which is designed to relay all traffic passing through it to all of its ports) will automatically begin sending all the traffic on that network segment to the sniffing device. On the other hand, a switch (which is designed to limit what traffic gets sent to which port) will have to be specially configured to send all traffic to the port where the sniffer is plugged in.

Another method for sniffing is to use a network tap--a device that literally splits a network transmission into two identical streams; one going to the original network destination and the other going to the sniffing device. Each of these methods has its advantages and disadvantages, including cost, feasibility, and the desire to maintain the secrecy of the sniffing activity.

The packets captured by sniffer are decoded and then displayed by the sniffer. Therefore, if the username/ password are contained in a packet or packets traversing the segment the sniffer is connected to, it will capture and display that information (and any other information on that segment it can see).

Of course, if the information is encrypted via a VPN, SSL, TLS, or similar technology, the information is still captured and displayed, but it is in an unreadable format.

The following answers are incorrect:

Data diddling involves changing data before, as it is entered into a computer, or after it is extracted.

Spoofing is forging an address and inserting it into a packet to disguise the origin of the communication - or causing a system to respond to the wrong address.

Surfing would refer to the surf attack, where an attacker sends spoofed packets to the broadcast address on a gateway in order to cause a denial of service.

CISA Review manual 2014 Page number 321

Official ISC2 Guide to the CISSP 3rd edition Page Number 153

QUESTION 406

Most access violations are:

- A. Accidental
- B. Caused by internal hackers
- C. Caused by external hackers
- D. Related to Internet

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The most likely source of exposure is from the uninformed, accidental or unknowing person, although the greatest impact may be from those with malicious or fraudulent intent. Reference: Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, Chapter 4: Protection of Information Assets (page 192).

QUESTION 407

Which of the following is NOT a component of IPSec?

- A. Authentication Header
- B. Encapsulating Security Payload
- C. Key Distribution Center
- D. Internet Key Exchange

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support AH, ESP and IKE are the three main components of IPSec. A KDC (Key Distribution Center) is a component of Kerberos, not IPSec.

Reference: Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, Chapter 4: Protection of Information Assets (page 217).

QUESTION 408

Which of the following statements pertaining to IPSec is incorrect?

- A. A security association has to be defined between two IPSec systems in order for bi-directional communication to be established.
- B. Integrity and authentication for IP datagrams are provided by AH.
- C. ESP provides for integrity, authentication and encryption to IP datagram's.
- D. In transport mode, ESP only encrypts the data payload of each packet.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support This is incorrect, there would be a pair of Security Association (SA) needed for bi directional communication and NOT only one SA. The sender and the receiver would both negotiate an SA for inbound and outbound connections.

The two main concepts of IPSec are Security Associations (SA) and tunneling. A Security Association (SA) is a simplex logical connection between two IPSec systems. For bi-directional communication to be established

between two IPSec systems, two separate Security Associations, one in each direction, must be defined.

The security protocols can either be AH or ESP.

The explanations below are a bit more thorough than what you need to know for the exam. However, they always say a picture is worth one thousand words, I think it is very true when it comes to explaining IPSEC and it's inner working. I have found a great article from CISCO PRESS and DLINK covering this subject, see references below.

Tunnel and Transport Modes

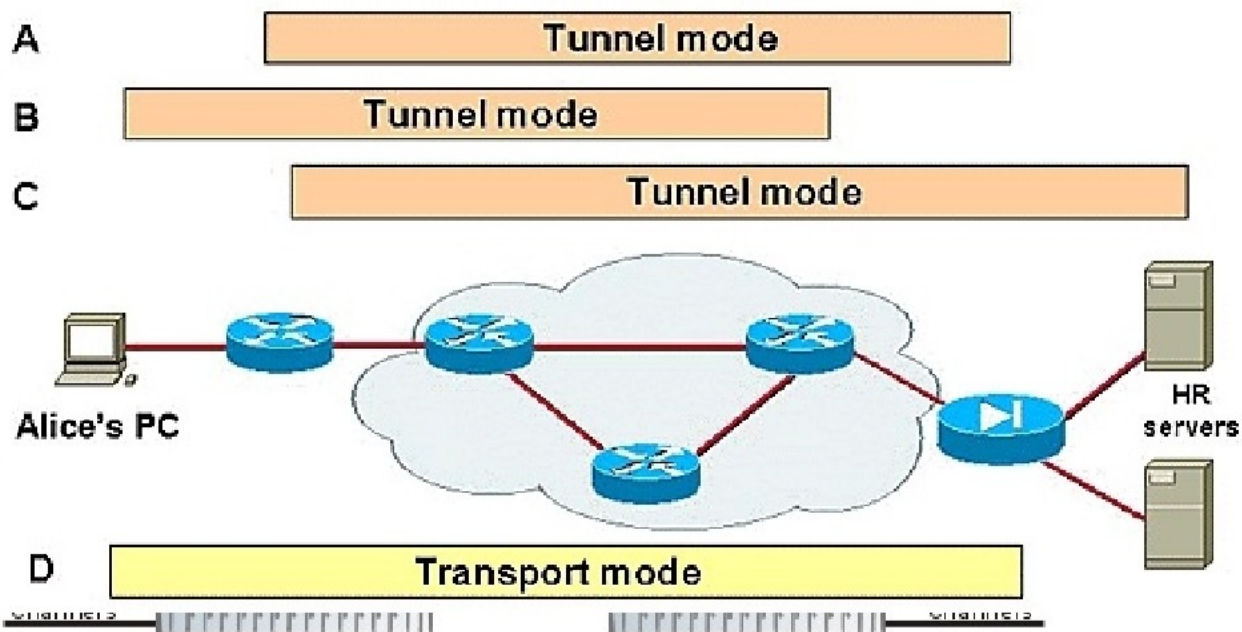
IPSec can be run in either tunnel mode or transport mode. Each of these modes has its own particular uses and care should be taken to ensure that the correct one is selected for the solution:

Tunnel mode is most commonly used between gateways, or at an end-station to a gateway, the gateway acting as a proxy for the hosts behind it.

Transport mode is used between end-stations or between an end-station and a gateway, if the gateway is being treated as a host--for example, an encrypted Telnet session from a workstation to a router, in which the router is the actual destination.

As you can see in the Figure 1 graphic below, basically transport mode should be used for end-to-end sessions and tunnel mode should be used for everything else.

FIGURE 1:



IPSEC Transport Mode versus Tunnel Mode

Tunnel and transport modes in IPSec.

Figure 1 above displays some examples of when to use tunnel versus transport mode:

Tunnel mode is most commonly used to encrypt traffic between secure IPSec gateways, such as between the Cisco router and PIX Firewall (as shown in example A in Figure 1). The IPSec gateways proxy IPSec for the devices behind them, such as Alice's PC and the HR servers in Figure 1. In example A, Alice connects to the HR servers securely through the IPSec tunnel set up between the gateways.

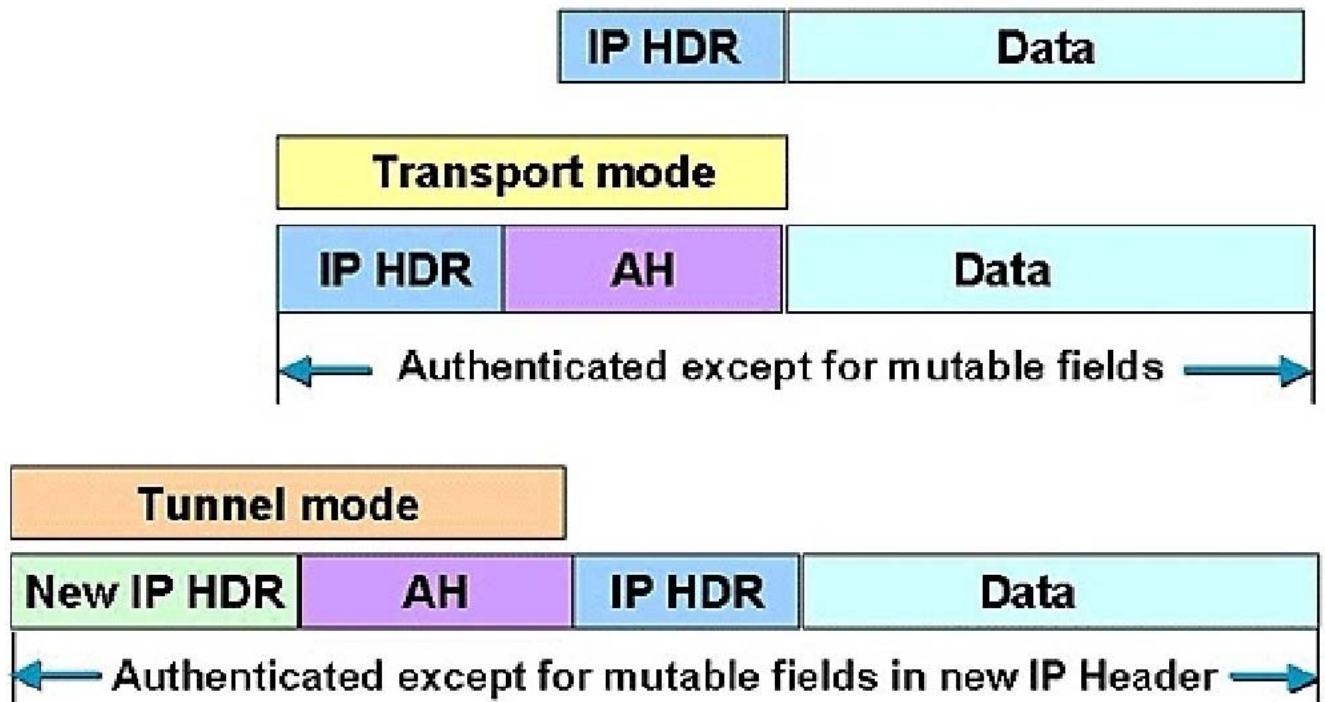
Tunnel mode is also used to connect an end-station running IPSec software, such as the Cisco Secure VPN Client, to an IPSec gateway, as shown in example B.

In example C, tunnel mode is used to set up an IPSec tunnel between the Cisco router and a server running IPSec software. Note that Cisco IOS software and the PIX Firewall sets tunnel mode as the default IPSec

mode.

Transport mode is used between end-stations supporting IPSec, or between an end-station and a gateway, if the gateway is being treated as a host. In example D, transport mode is used to set up an encrypted Telnet session from Alice's PC running Cisco Secure VPN Client software to terminate at the PIX Firewall, enabling Alice to remotely configure the PIX Firewall securely.

FIGURE 2:



IPSEC AH Tunnel and Transport mode

AH Tunnel Versus Transport Mode

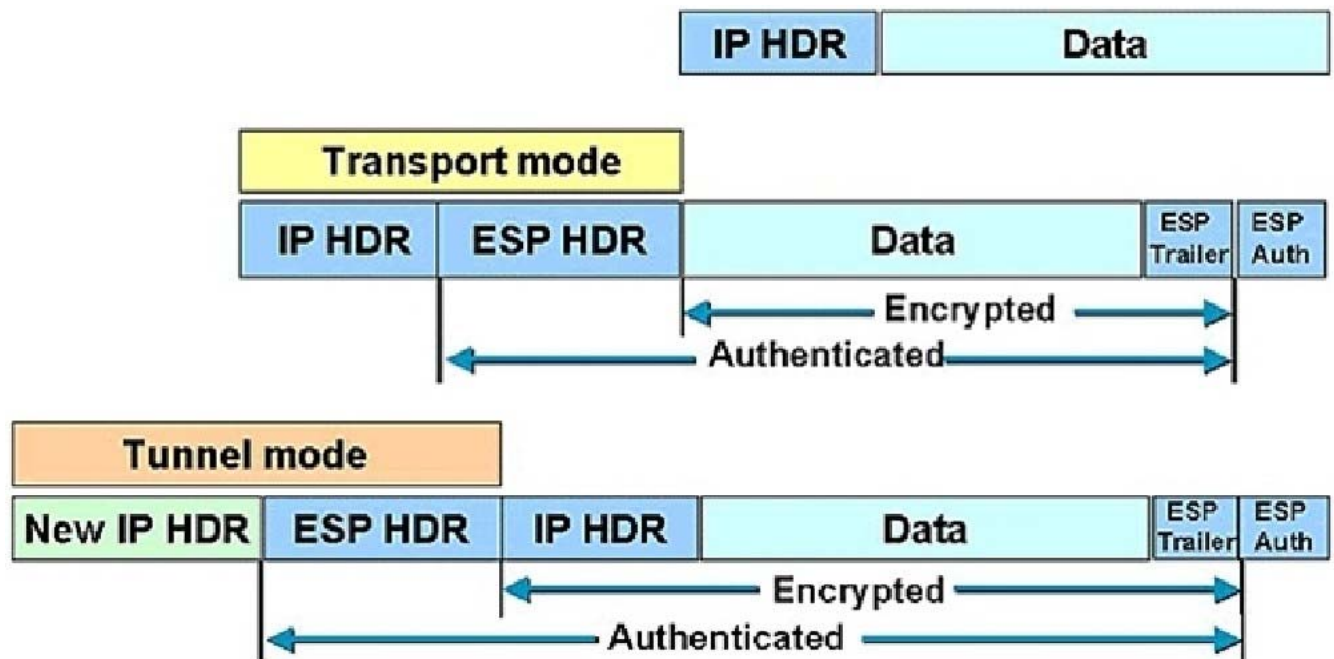
Figure 2 above, shows the differences that the IPsec mode makes to AH. In transport mode, AH services protect the external IP header along with the data payload. AH services protect all the fields in the header that don't change in transport. The header goes after the IP header and before the ESP header, if present, and other higher-layer protocols.

As you can see in Figure 2 above, In tunnel mode, the entire original header is authenticated, a new IP header is built, and the new IP header is protected in the same way as the IP header in transport mode.

AH is incompatible with Network Address Translation (NAT) because NAT changes the source IP address, which breaks the AH header and causes the packets to be rejected by the IPsec peer.

FIGURE: 3

IPSEC ESP Tunnel versus Transport modes



ESP Tunnel Versus Transport Mode

Figure 3 above shows the differences that the IPsec mode makes to ESP. In transport mode, the IP payload is encrypted and the original headers are left intact. The ESP header is inserted after the IP header and before the upper-layer protocol header. The upper-layer protocols are encrypted and authenticated along with the ESP header. ESP doesn't authenticate the IP header itself.

NOTE: Higher-layer information is not available because it's part of the encrypted payload.

When ESP is used in tunnel mode, the original IP header is well protected because the entire original IP datagram is encrypted. With an ESP authentication mechanism, the original IP datagram and the ESP header are included; however, the new IP header is not included in the authentication.

When both authentication and encryption are selected, encryption is performed first, before authentication. One reason for this order of processing is that it facilitates rapid detection and rejection of replayed or bogus packets by the receiving node. Prior to decrypting the packet, the receiver can detect the problem and potentially reduce the impact of denial-of-service attacks.

ESP can also provide packet authentication with an optional field for authentication. Cisco IOS software and the PIX Firewall refer to this service as ESP hashed message authentication code (HMAC). Authentication is calculated after the encryption is done. The current IPSec standard specifies which hashing algorithms have to be supported as the mandatory HMAC algorithms.

The main difference between the authentication provided by ESP and AH is the extent of the coverage. Specifically, ESP doesn't protect any IP header fields unless those fields are encapsulated by ESP (tunnel mode).

The following were incorrect answers for this question:

Integrity and authentication for IP datagrams are provided by AH This is correct, AH provides integrity and authentication and ESP provides integrity, authentication and encryption.

ESP provides for integrity, authentication and encryption to IP datagram's. ESP provides authentication, integrity, and confidentiality, which protect against data tampering and, most importantly, provide message content protection.

In transport mode, ESP only encrypts the data payload of each packet. ESP can be operated in either tunnel mode (where the original packet is encapsulated into a new one) or transport mode (where only the data payload of each packet is encrypted, leaving the header untouched). Hernandez CISSP, Steven (2012-12-21). Official (ISC)2 Guide to the CISSP CBK, Third Edition ((ISC)2 Press) (Kindle Locations 6986-6989). Acerbic Publications. Kindle Edition.

and
<http://www.ciscopress.com/articles/article.asp?p=25477>

and
<http://documentation.netgear.com/reference/sve/vpn/VPNBasics-3-05.html>

QUESTION 409

As an IS auditor it is very important to understand software release management process. Which of the following software release normally contains a significant change or addition of new functionality?

- A. Major software Release
- B. Minor software Release
- C. Emergency software release
- D. General software Release

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support A major release usually introduces new capabilities or functions. Major releases may accumulate all the changes from previous minor releases. Major releases advance the version number by a full increment, for example, from version 5.70 to version 6.

For CISA exam you should know below information about software release management:

Software Release Management is the process of ensuring releases can be reliably planned, scheduled and successfully transitioned (deployed) to Test and Live Environments. Software Release Management is not just about "automating the path to production" although that is certainly an important part. It also about adopting a holistic view of application changes, using the "Release" as the container to ensure that changes are packaged, released and tested in a repeatable and controlled manner.

Release Management is often likened to the conductor of an orchestra, with the individual changes to be implemented the various instruments within it. Software Release Management is intrinsically linked with the more well understood and adopted Software Change and Configuration Management disciplines.

Software Release management is a process through which software is made available to user. Each update or upgrade of a Configuration Item is referred to as a release.

There are three levels of releases. These levels related to releasing hardware or software into your IT infrastructure. Some may be a single change, others may implement many changes at a time. Major - A major release usually introduces new capabilities or functions. Major releases may accumulate all the changes from previous minor releases. Major releases advance the version number by a full increment, for example, from version 5.70 to version 6.

Minor - Minor releases incorporate a number of fixes for known problems into the baseline, or trusted state, of an item. Minor releases usually increment the version number at the first decimal place. For example, version 6.10 would change to version 6.20.

Emergency - Emergency releases are quick fixes to repair unexpected problems or temporary measures to prevent the interruption of critical services.

The following were incorrect answers:

Minor - Minor releases incorporate a number of fixes for known problems into the baseline, or trusted state, of an item. Minor releases usually increment the version number at the first decimal place. For example, version 6.10 would change to version 6.20.

Emergency - Emergency releases are quick fixes to repair unexpected problems or temporary measures to prevent the interruption of critical services.

General software Release Not a valid type of software release.
CISA review manual 2014 Page number 244

QUESTION 410

As an IS auditor it is very important to understand software release management process. Which of the following software release normally contains small enhancements and fixes?

- A. Major software Release
- B. Minor software Release
- C. Emergency software release
- D. General software Release

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Minor releases incorporate a number of fixes for known problems into the baseline, or trusted state, of an item. Minor releases usually increment the version number at the first decimal place. For example, version 6.10 would change to version 6.20.

For CISA exam you should know below information about software release management:

Software Release Management is the process of ensuring releases can be reliably planned, scheduled and successfully transitioned (deployed) to Test and Live Environments. Software Release Management is not just about "automating the path to production" although that is certainly an important part. It also about adopting a holistic view of application changes, using the "Release" as the container to ensure that changes are packaged, released and tested in a repeatable and controlled manner. Release Management is often likened to the conductor of an orchestra, with the individual changes to be implemented the various instruments within it. Software Release Management is intrinsically linked with the more well understood and adopted Software Change and Configuration Management disciplines.

Software Release management is a process through which software is made available to user. Each update or upgrade of a Configuration Item is referred to as a release.

There are three levels of releases. These levels related to releasing hardware or software into your IT infrastructure. Some may be a single change, others may implement many changes at a time. Major - A major release usually introduces new capabilities or functions. Major releases may accumulate all the changes from previous minor releases. Major releases advance the version number by a full increment, for example, from version 5.70 to version 6. Minor - Minor releases incorporate a number of fixes for known problems into the baseline, or trusted state, of

an item. Minor releases usually increment the version number at the first decimal place. For example, version 6.10 would change to version 6.20.

Emergency - Emergency releases are quick fixes to repair unexpected problems or temporary measures to prevent the interruption of critical services.

The following were incorrect answers:

Major - A major release usually introduces new capabilities or functions. Major releases may accumulate all the changes from previous minor releases. Major releases advance the version number by a full increment, for example, from version 5.70 to version 6.

Emergency - Emergency releases are quick fixes to repair unexpected problems or temporary measures to prevent the interruption of critical services.

General software Release Not a valid type of software release.

CISA review manual 2014 Page number 244

QUESTION 411

In which of the following database model is the data organized into a tree-like structure, implying a single parent for each record?

- A. Hierarchical database model
- B. Network database model
- C. Relational database model
- D. Object-relational database model

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support In a hierarchical model, data is organized into a tree-like structure, implying a single parent for each record. A sort field keeps sibling records in a particular order.

For your exam you should know below information about database models:

A database model is a type of data model that determines the logical structure of a database and fundamentally determines in which manner data can be stored, organized, and manipulated. The most popular example of a database model is the relational model, which uses a table-based format.

Common logical data models for databases include:

Hierarchical database model
Network model
Relational model
Object-relational database models

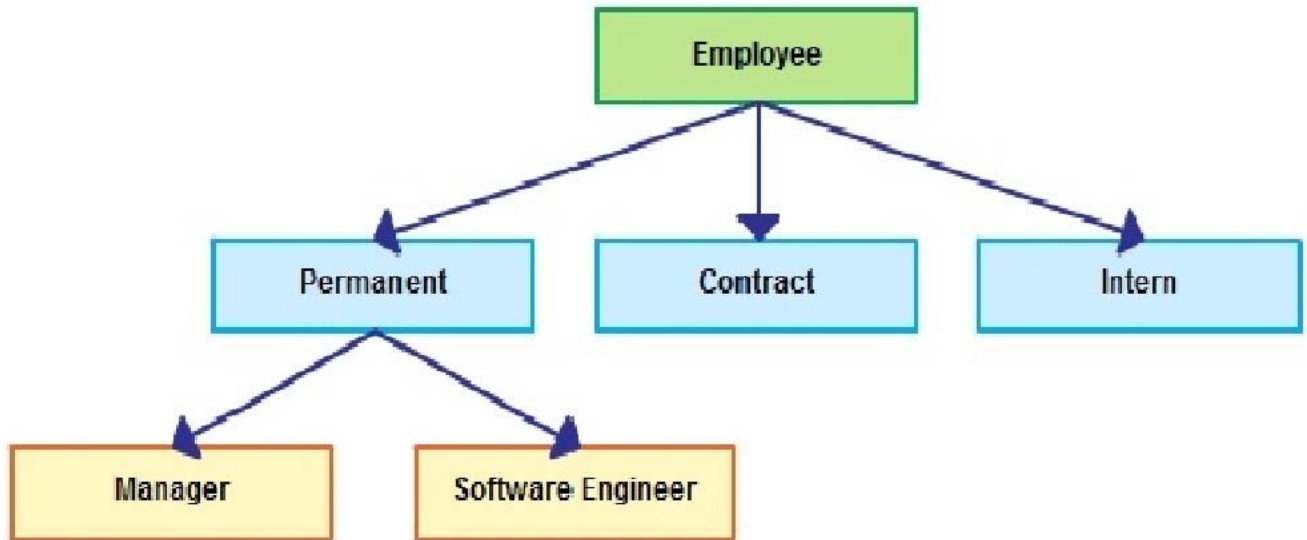
Hierarchical database model

In a hierarchical model, data is organized into a tree-like structure, implying a single parent for each record. A sort field keeps sibling records in a particular order. Hierarchical structures were widely used in the early mainframe database management systems, such as the Information Management System (IMS) by IBM, and now describe the structure of XML documents. This structure allows one one-to-many relationship between two types of data. This structure is very efficient to describe many relationships in the real world; recipes, table of contents, ordering of paragraphs/verses, any nested and sorted information.

This hierarchy is used as the physical order of records in storage. Record access is done by navigating

through the data structure using pointers combined with sequential accessing. Because of this, the hierarchical structure is inefficient for certain database operations when a full path (as opposed to upward link and sort field) is not also included for each record. Such limitations have been compensated for in later IMS versions by additional logical hierarchies imposed on the base physical hierarchy.

Hierarchical database model



Network database model

The network model expands upon the hierarchical structure, allowing many-to-many relationships in a tree-like structure that allows multiple parents. It was the most popular before being replaced by the relational model, and is defined by the CODASYL specification.

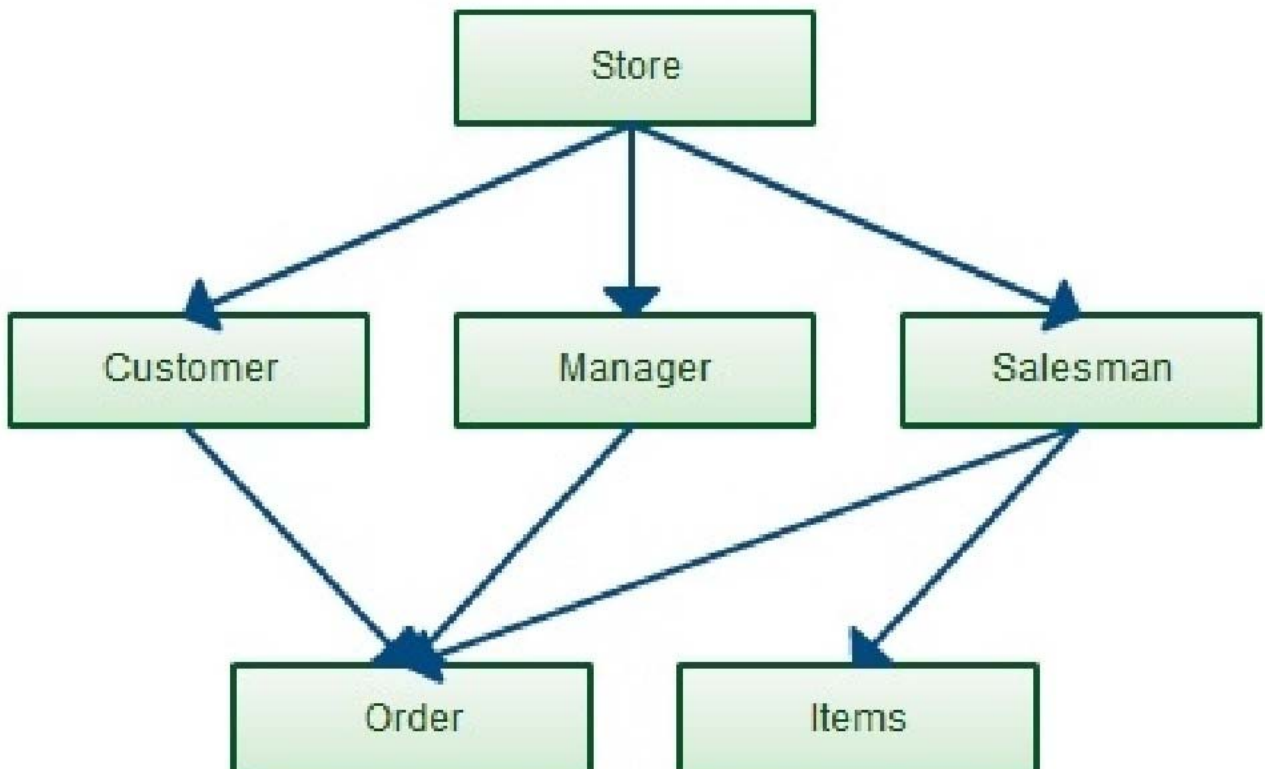
The network model organizes data using two fundamental concepts, called records and sets. Records contain fields (which may be organized hierarchically, as in the programming language COBOL). Sets (not to be confused with mathematical sets) define one-to-many[disambiguation needed] relationships between records: one owner, many members. A record may be an owner in any number of sets, and a member in any number of sets.

A set consists of circular linked lists where one record type, the set owner or parent, appears once in each circle, and a second record type, the subordinate or child, may appear multiple times in each circle. In this way a hierarchy may be established between any two record types, e.g., type A is the owner of B. At the same time another set may be defined where B is the owner of A. Thus all the sets comprise a general directed graph (ownership defines a direction), or network construct. Access to records is either sequential (usually in each record type) or by navigation in the circular linked lists.

The network model is able to represent redundancy in data more efficiently than in the hierarchical model, and

there can be more than one path from an ancestor node to a descendant. The operations of the network model are navigational in style: a program maintains a current position, and navigates from one record to another by following the relationships in which the record participates. Records can also be located by supplying key values.

Network Database model



Relational database model

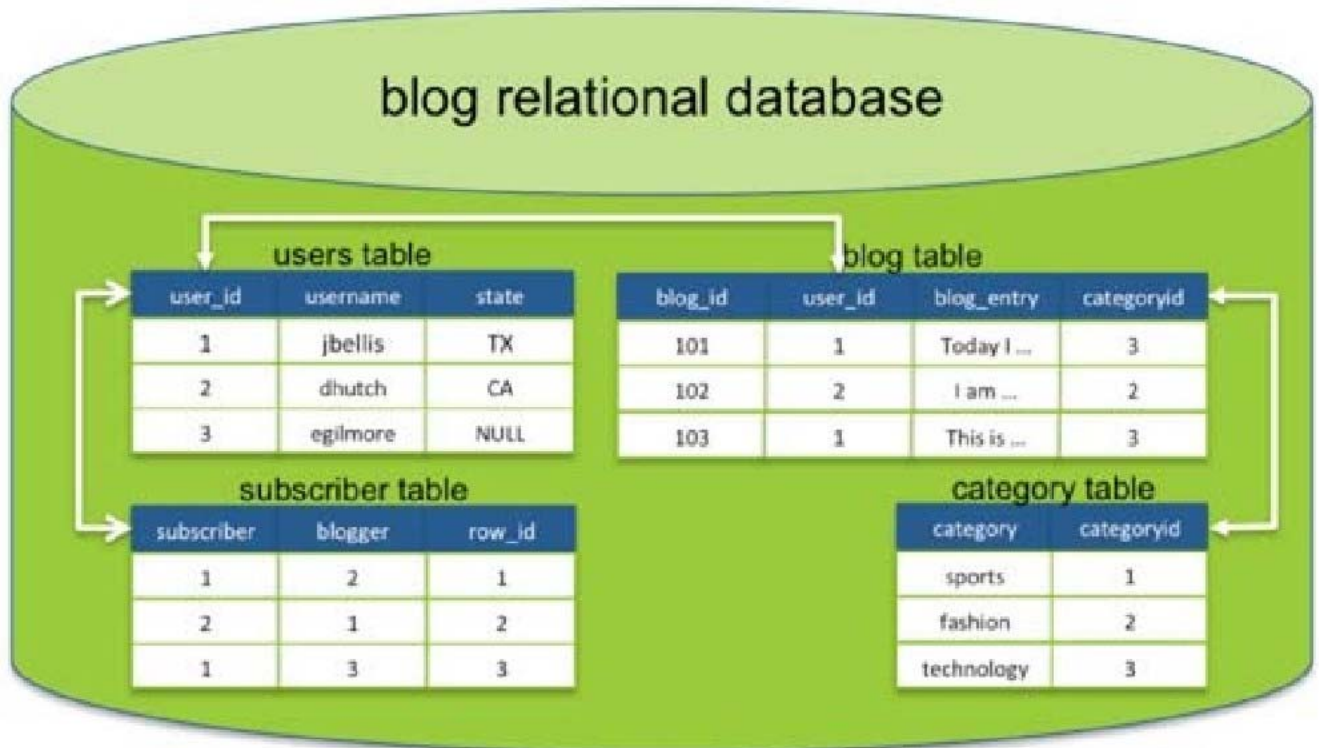
In the relational model of a database, all data is represented in terms of tuples, grouped into relations. A database organized in terms of the relational model is a relational database.

In the relational model, related records are linked together with a "key".

The purpose of the relational model is to provide a declarative method for specifying data and queries: users directly state what information the database contains and what information they want from it, and let the database management system software take care of describing data structures for storing the data and retrieval procedures for answering queries.

Most relational databases use the SQL data definition and query language; these systems implement what can be regarded as an engineering approximation to the relational model. A table in an SQL database schema corresponds to a predicate variable; the contents of a table to a relation; key constraints, other constraints, and SQL queries correspond to predicates. However, SQL databases, including DB2, deviate from the relational model in many details, and Cod fiercely argued against deviations that compromise the original principles.

Relational database model



Object-relational database Model

An object-relational database (ORD), or object-relational database management system (ORDBMS), is a database management system (DBMS) similar to a relational database, but with an object-oriented database model: objects, classes and inheritance are directly supported in database schemas and in the query language. In addition, just as with pure relational systems, it supports extension of the data model with custom data-types and methods.

Example of an object-oriented database model

An object-relational database can be said to provide a middle ground between relational databases and object-oriented databases (OODBMS). In object-relational databases, the approach is essentially that of relational databases: the data resides in the database and is manipulated collectively with queries in a query language; at the other extreme are OODBMSes in which the database is essentially a persistent object store for software written in an object-oriented programming language, with a programming API for storing and

retrieving objects, and little or no specific support for querying.

The following were incorrect answers:

Network model-The network model expands upon the hierarchical structure, allowing many-to-many relationships in a tree-like structure that allows multiple parents. Relational model- In the relational model of a database, all data is represented in terms of tuples, grouped into relations. A database organized in terms of the relational model is a relational database. In the relational model, related records are linked together with a "key".

Object-relational database models- An object-relational database can be said to provide a middle ground between relational databases and object-oriented databases (OODBMS). In object-relational databases, the approach is essentially that of relational databases: the data resides in the database and is manipulated collectively with queries in a query language; at the other extreme are OODBMSes in which the database is essentially a persistent object store for software written in an object-oriented programming language, with a programming API for storing and retrieving objects, and little or no specific support for querying.

CISA review manual 2014 Page number 254

QUESTION 412

Which of the following database model allow many-to-many relationships in a tree-like structure that allows multiple parents?

- A. Hierarchical database model
- B. Network database model
- C. Relational database model
- D. Object-relational database model

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Network database model-The network model expands upon the hierarchical structure, allowing

many-to-many relationships in a tree-like structure that allows multiple parents.

For your exam you should know below information about database models:

A database model is a type of data model that determines the logical structure of a database and fundamentally determines in which manner data can be stored, organized, and manipulated. The most popular example of a database model is the relational model, which uses a table-based format.

Common logical data models for databases include:

Hierarchical database model

Network model

Relational model

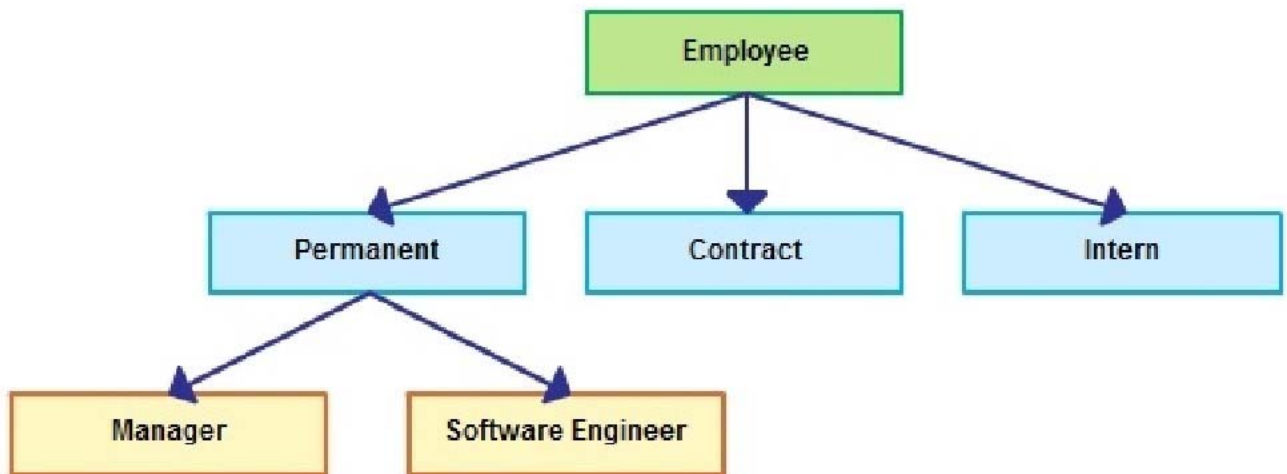
Object-relational database models

Hierarchical database model

In a hierarchical model, data is organized into a tree-like structure, implying a single parent for each record. A sort field keeps sibling records in a particular order. Hierarchical structures were widely used in the early mainframe database management systems, such as the Information Management System (IMS) by IBM, and now describe the structure of XML documents. This structure allows one one-to-many relationship between two types of data. This structure is very efficient to describe many relationships in the real world; recipes, table of contents, ordering of paragraphs/verses, any nested and sorted information.

This hierarchy is used as the physical order of records in storage. Record access is done by navigating through the data structure using pointers combined with sequential accessing. Because of this, the hierarchical structure is inefficient for certain database operations when a full path (as opposed to upward link and sort field) is not also included for each record. Such limitations have been compensated for in later IMS versions by additional logical hierarchies imposed on the base physical hierarchy.

Hierarchical database model



Network database model

The network model expands upon the hierarchical structure, allowing many-to-many relationships in a tree-like structure that allows multiple parents. It was the most popular before being replaced by the relational model, and is defined by the CODASYL specification.

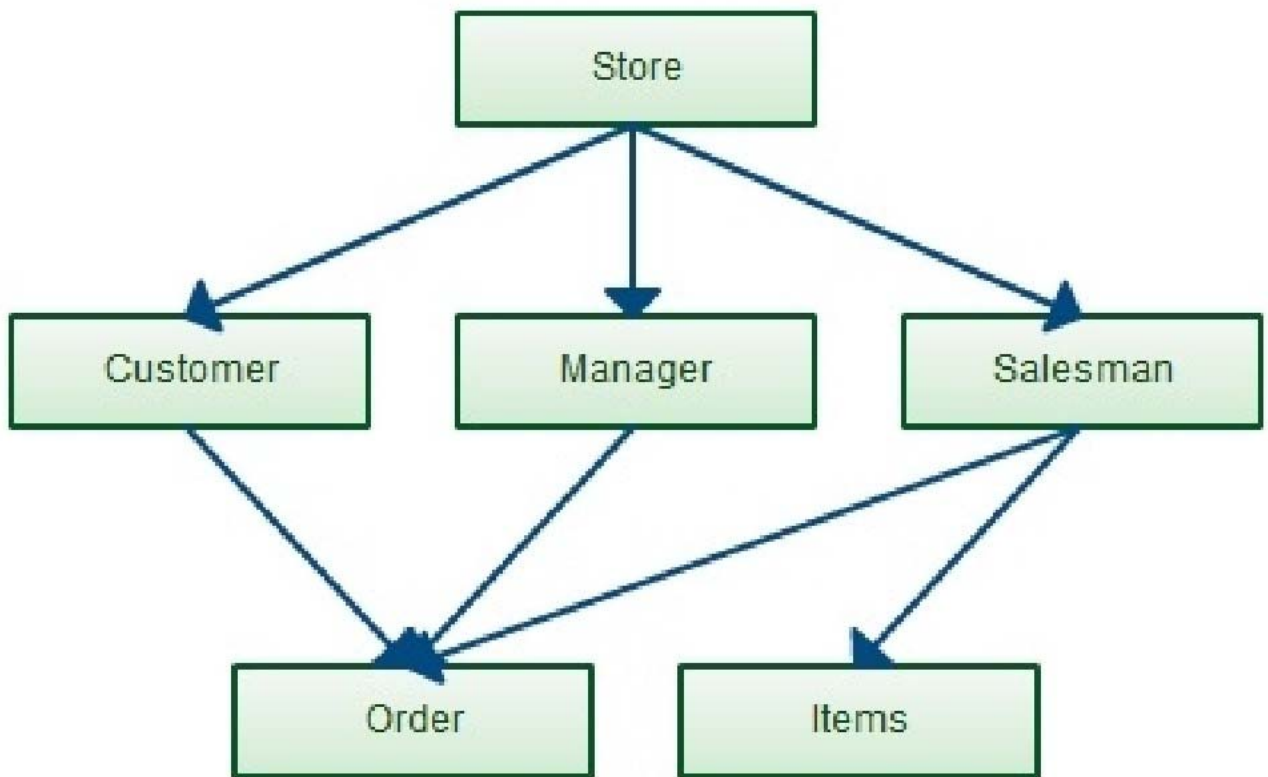
The network model organizes data using two fundamental concepts, called records and sets. Records contain fields (which may be organized hierarchically, as in the programming language COBOL). Sets (not to be confused with mathematical sets) define one-to-many[disambiguation needed] relationships between records: one owner, many members. A record may be an owner in any number of sets, and a member in any number of sets.

A set consists of circular linked lists where one record type, the set owner or parent, appears once in each circle, and a second record type, the subordinate or child, may appear multiple times in each circle. In this way a hierarchy may be established between any two record types, e.g., type A is the owner of B. At the same time another set may be defined where B is the owner of A. Thus all the sets comprise a general directed graph (ownership defines a direction), or network construct. Access to records is either sequential (usually in each record type) or by navigation in the circular linked lists.

The network model is able to represent redundancy in data more efficiently than in the hierarchical model, and there can be more than one path from an ancestor node to a descendant. The operations of the network model

are navigational in style: a program maintains a current position, and navigates from one record to another by following the relationships in which the record participates. Records can also be located by supplying key values.

Network Database model



Relational database model

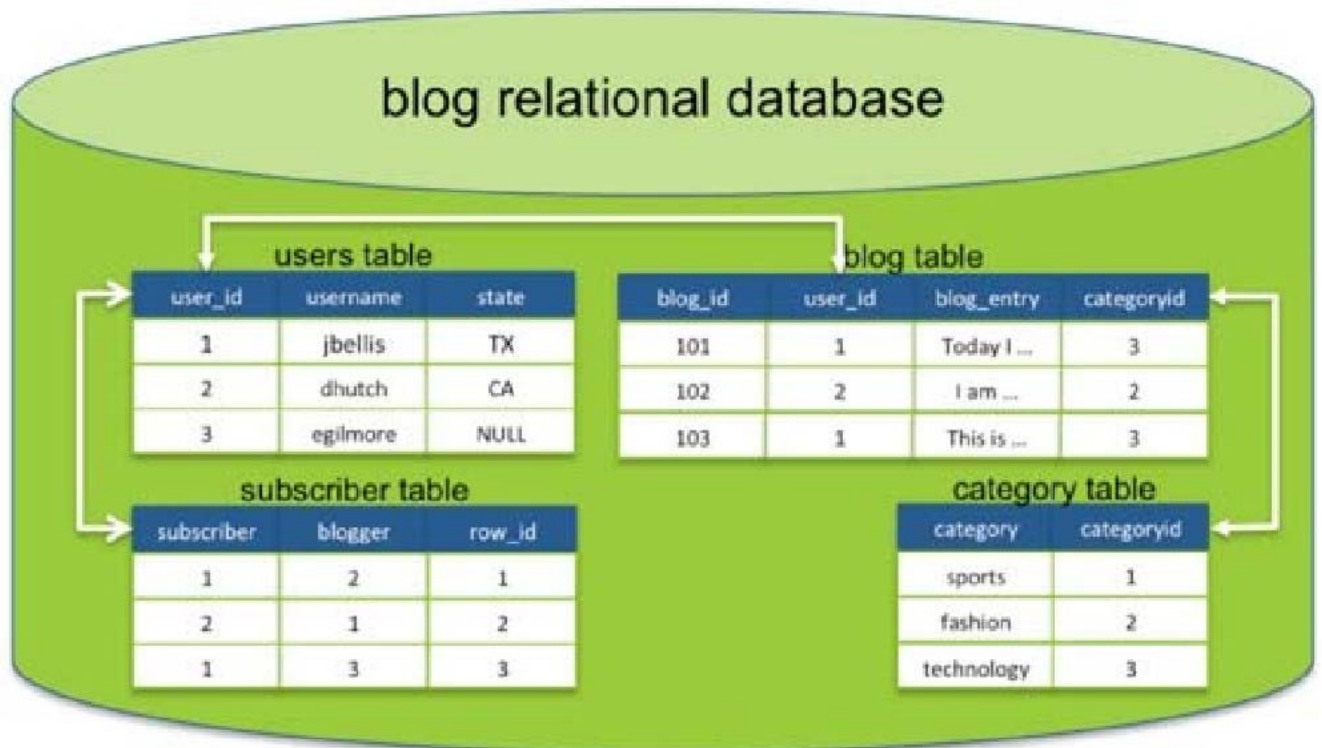
In the relational model of a database, all data is represented in terms of tuples, grouped into relations. A database organized in terms of the relational model is a relational database.

In the relational model, related records are linked together with a "key".

The purpose of the relational model is to provide a declarative method for specifying data and queries: users directly state what information the database contains and what information they want from it, and let the database management system software take care of describing data structures for storing the data and retrieval procedures for answering queries.

Most relational databases use the SQL data definition and query language; these systems implement what can be regarded as an engineering approximation to the relational model. A table in an SQL database schema corresponds to a predicate variable; the contents of a table to a relation; key constraints, other constraints, and SQL queries correspond to predicates. However, SQL databases, including DB2, deviate from the relational model in many details, and Cod fiercely argued against deviations that compromise the original principles.

Relational database model



Object-relational database Model

An object-relational database (ORD), or object-relational database management system (ORDBMS), is a database management system (DBMS) similar to a relational database, but with an object-oriented database model: objects, classes and inheritance are directly supported in database schemas and in the query language. In addition, just as with pure relational systems, it supports extension of the data model with custom data-types and methods.

Example of an object-oriented database model

An object-relational database can be said to provide a middle ground between relational databases and object-oriented databases (OODBMS). In object-relational databases, the approach is essentially that of relational databases: the data resides in the database and is manipulated collectively with queries in a query language; at the other extreme are OODBMSes in which the database is essentially a persistent object store for software written in an object-oriented programming language, with a programming API for storing and retrieving objects, and little or no specific support for querying.

The following were incorrect answers:

Hierarchical database model - In a hierarchical model, data is organized into a tree-like structure, implying a single parent for each record. A sort field keeps sibling records in a particular order. **Relational model** - In the relational model of a database, all data is represented in terms of tuples, grouped into relations. A database organized in terms of the relational model is a relational database. In the relational model, related records are linked together with a "key". **Object-relational database models** - An object-relational database can be said to provide a middle ground between relational databases and object-oriented databases (OODBMS). In object-relational databases, the approach is essentially that of relational databases: the data resides in the database and is manipulated collectively with queries in a query language; at the other extreme are OODBMSes in which the database is essentially a persistent object store for software written in an object-oriented programming language, with a programming API for storing and retrieving objects, and little or no specific support for querying. CISA review manual 2014 Page number 254

QUESTION 413

In which of the following database models is the data represented in terms of tuples and grouped into relations?

- A. Hierarchical database model
- B. Network database model
- C. Relational database model
- D. Object-relational database model

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support In the relational model of a database, all data is represented in terms of tuples, grouped into relations. A database organized in terms of the relational model is a relational database.

For your exam you should know below information about database models:

A database model is a type of data model that determines the logical structure of a database and fundamentally determines in which manner data can be stored, organized, and manipulated. The most popular example of a database model is the relational model, which uses a table-based format.

Common logical data models for databases include:

- Hierarchical database model
- Network model
- Relational model
- Object-relational database models

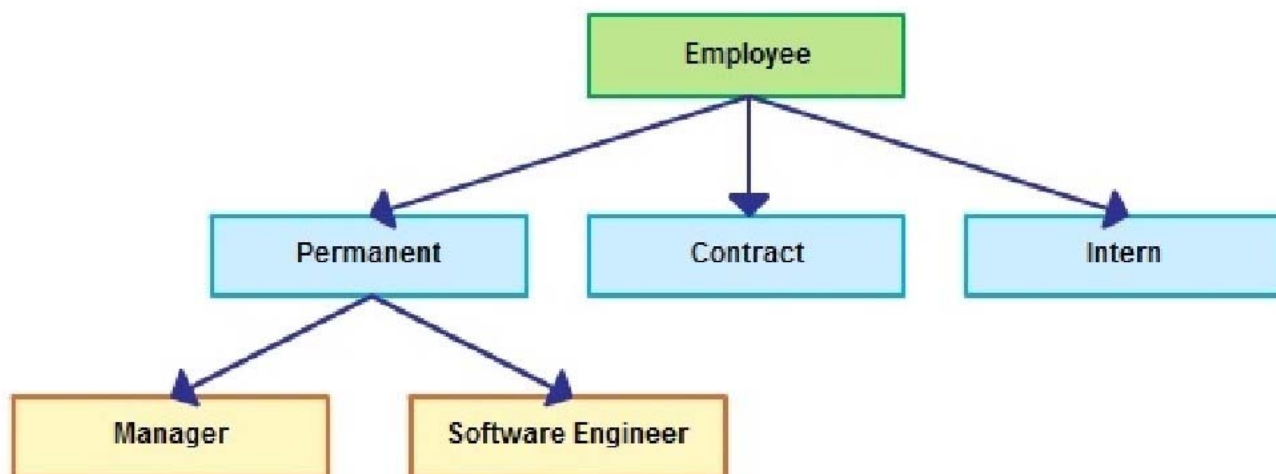
Hierarchical database model

In a hierarchical model, data is organized into a tree-like structure, implying a single parent for each record. A sort field keeps sibling records in a particular order. Hierarchical structures were widely used in the early mainframe database management systems, such as the Information Management System (IMS) by IBM, and now describe the structure of XML documents. This structure allows one one-to-many relationship between two types of data. This structure is very efficient to describe many relationships in the real world; recipes, table of contents, ordering of paragraphs/verses, any nested and sorted information.

This hierarchy is used as the physical order of records in storage. Record access is done by navigating through the data structure using pointers combined with sequential accessing. Because of this, the hierarchical structure is inefficient for certain database operations when a full path (as opposed to upward link and sort

field) is not also included for each record. Such limitations have been compensated for in later IMS versions by additional logical hierarchies imposed on the base physical hierarchy.

Hierarchical database model



Network database model

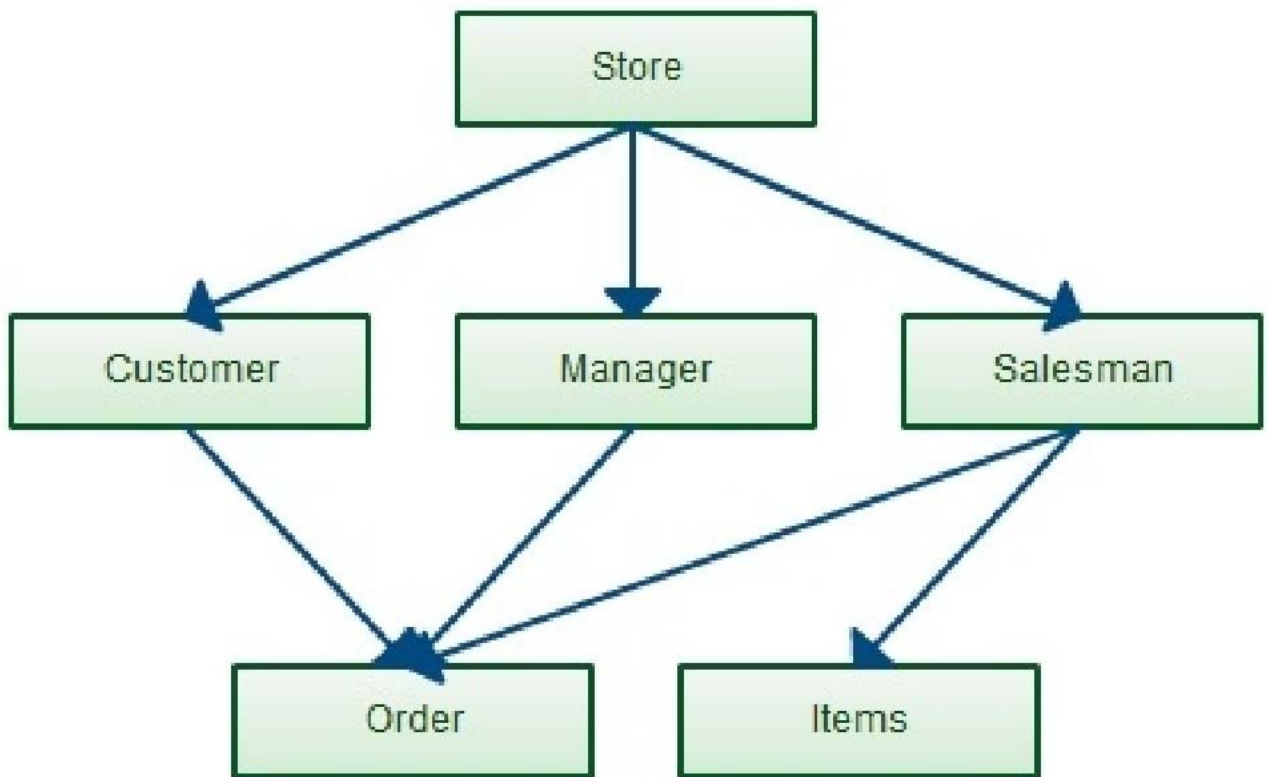
The network model expands upon the hierarchical structure, allowing many-to-many relationships in a tree-like structure that allows multiple parents. It was the most popular before being replaced by the relational model, and is defined by the CODASYL specification.

The network model organizes data using two fundamental concepts, called records and sets. Records contain fields (which may be organized hierarchically, as in the programming language COBOL). Sets (not to be confused with mathematical sets) define one-to-many[disambiguation needed] relationships between records: one owner, many members. A record may be an owner in any number of sets, and a member in any number of sets.

A set consists of circular linked lists where one record type, the set owner or parent, appears once in each circle, and a second record type, the subordinate or child, may appear multiple times in each circle. In this way a hierarchy may be established between any two record types, e.g., type A is the owner of B. At the same time another set may be defined where B is the owner of A. Thus all the sets comprise a general directed graph (ownership defines a direction), or network construct. Access to records is either sequential (usually in each record type) or by navigation in the circular linked lists.

The network model is able to represent redundancy in data more efficiently than in the hierarchical model, and there can be more than one path from an ancestor node to a descendant. The operations of the network model are navigational in style: a program maintains a current position, and navigates from one record to another by following the relationships in which the record participates. Records can also be located by supplying key values.

Network Database model



Relational database model

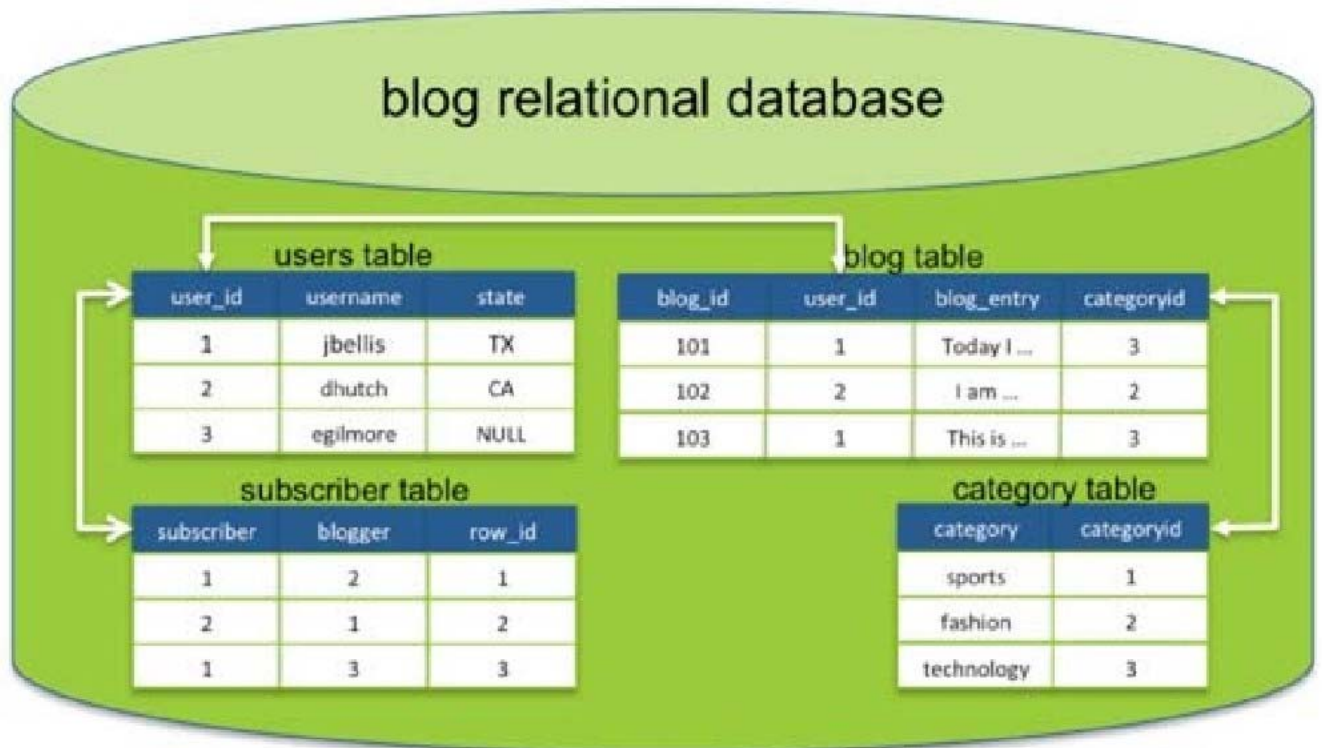
In the relational model of a database, all data is represented in terms of tuples, grouped into relations. A database organized in terms of the relational model is a relational database.

In the relational model, related records are linked together with a "key".

The purpose of the relational model is to provide a declarative method for specifying data and queries: users directly state what information the database contains and what information they want from it, and let the database management system software take care of describing data structures for storing the data and retrieval procedures for answering queries.

Most relational databases use the SQL data definition and query language; these systems implement what can be regarded as an engineering approximation to the relational model. A table in an SQL database schema corresponds to a predicate variable; the contents of a table to a relation; key constraints, other constraints, and SQL queries correspond to predicates. However, SQL databases, including DB2, deviate from the relational model in many details, and Cod

Relational database model



Object-relational database Model

An object-relational database (ORD), or object-relational database management system (ORDBMS), is a database management system (DBMS) similar to a relational database, but with an object-oriented database model: objects, classes and inheritance are directly supported in database schemas and in the query language. In addition, just as with pure relational systems, it supports extension of the data model with custom data-types and methods.

Example of an object-oriented database model

An object-relational database can be said to provide a middle ground between relational databases and object-oriented databases (OODBMS). In object-relational databases, the approach is essentially that of relational databases: the data resides in the database and is manipulated collectively with queries in a query language; at the other extreme are OODBMSes in which the database is essentially a persistent object store

for software written in an object-oriented programming language, with a programming API for storing and retrieving objects, and little or no specific support for querying.

The following were incorrect answers:

Hierarchical database model - In a hierarchical model, data is organized into a tree-like structure, implying a single parent for each record. A sort field keeps sibling records in a particular order. Network database model-The network model expands upon the hierarchical structure, allowing many-to-many relationships in a tree-like structure that allows multiple parents. Object-relational database models- An object-relational database can be said to provide a middle ground between relational databases and object-oriented databases (OODBMS). In object-relational databases, the approach is essentially that of relational databases: the data resides in the database and is manipulated collectively with queries in a query language; at the other extreme are OODBMSes in which the database is essentially a persistent object store for software written in an object-oriented programming language, with a programming API for storing and retrieving objects, and little or no specific support for querying.

CISA review manual 2014 Page number 254

QUESTION 414

Which of the following is a type of computer network used for data transmission among devices such as computers, telephones and personal digital assistants?

- A. LAN
- B. WAN
- C. SAN
- D. PAN

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 415

Which of the following type of a computer network covers a limited area such as a home, office or campus?

- A. LAN
- B. WAN
- C. SAN
- D. PAN

Correct Answer: A

Explanation

Explanation/Reference:

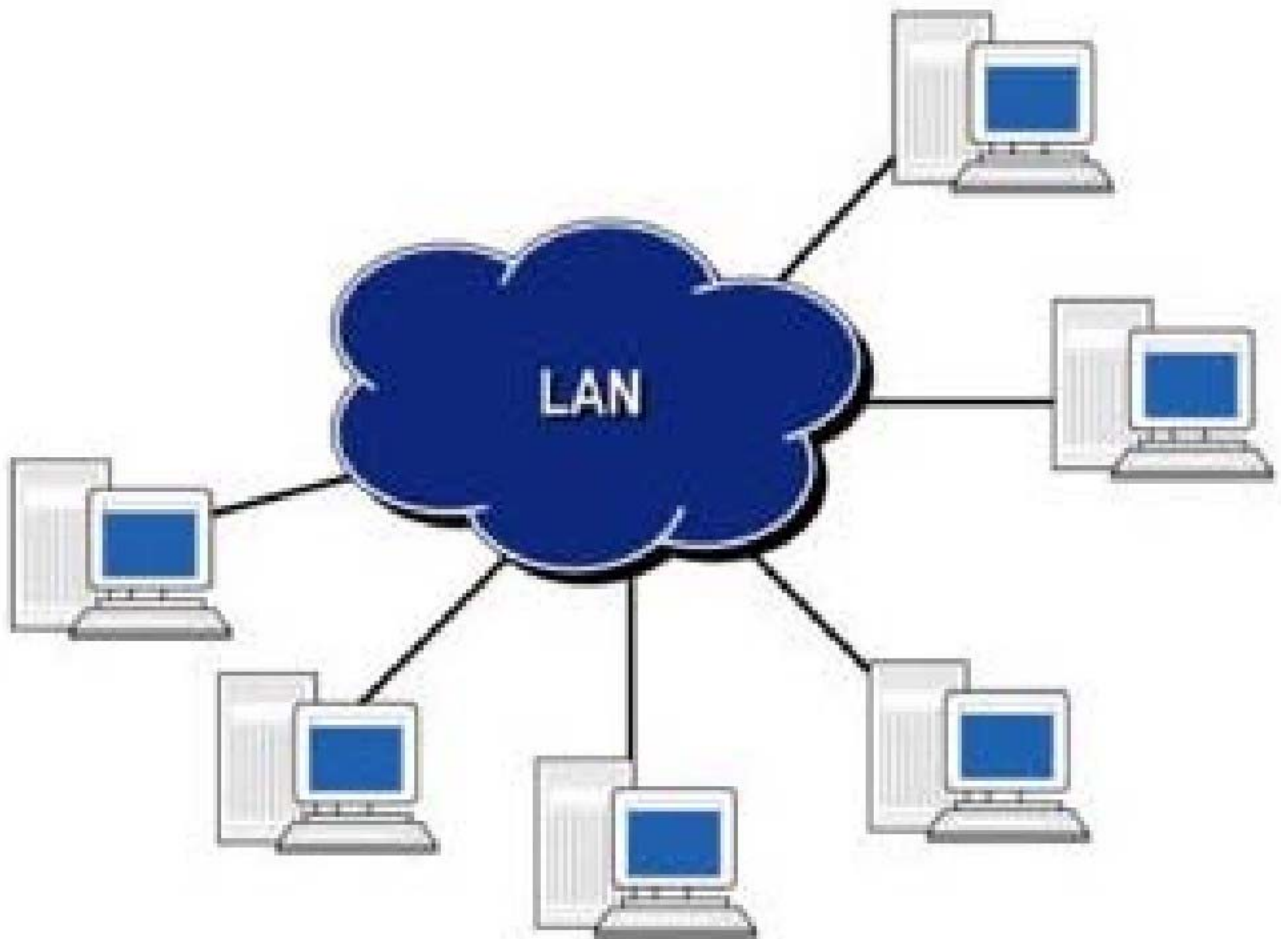
Section: Information System Operations, Maintenance and Support A local area network (LAN) is a computer network that interconnects computers within a limited area such as a home, school, computer laboratory, or office building using network media.

For your exam you should know below information about computer networks:

Local Area Network (LAN)

A local area network (LAN) is a computer network that interconnects computers within a limited area such as a home, school, computer laboratory, or office building using network media.

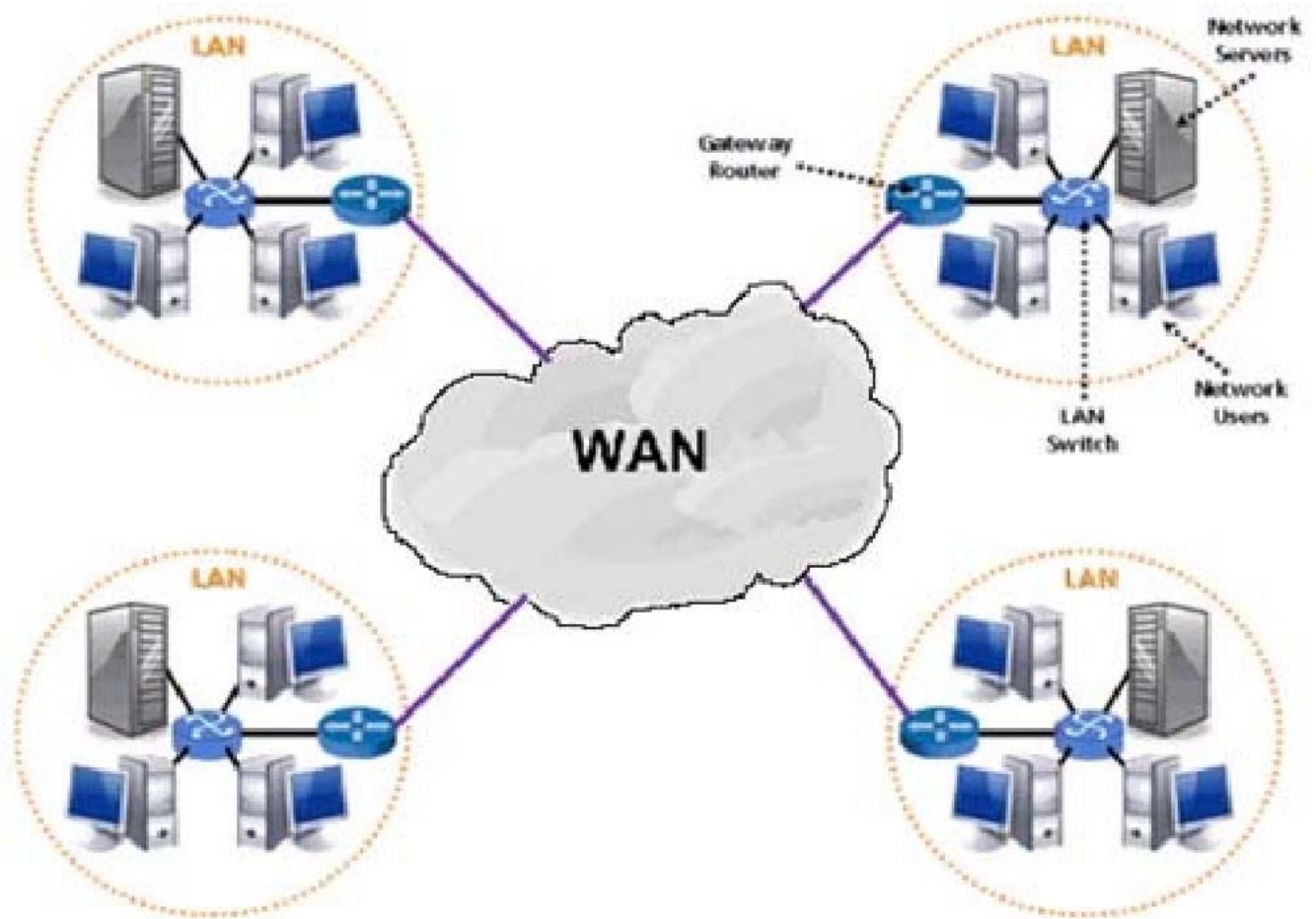
Local Area Network



Wide Area Network

A wide area network (WAN) is a network that covers a broad area (i.e., any telecommunications network that links across metropolitan, regional, national or international boundaries) using leased telecommunication lines.

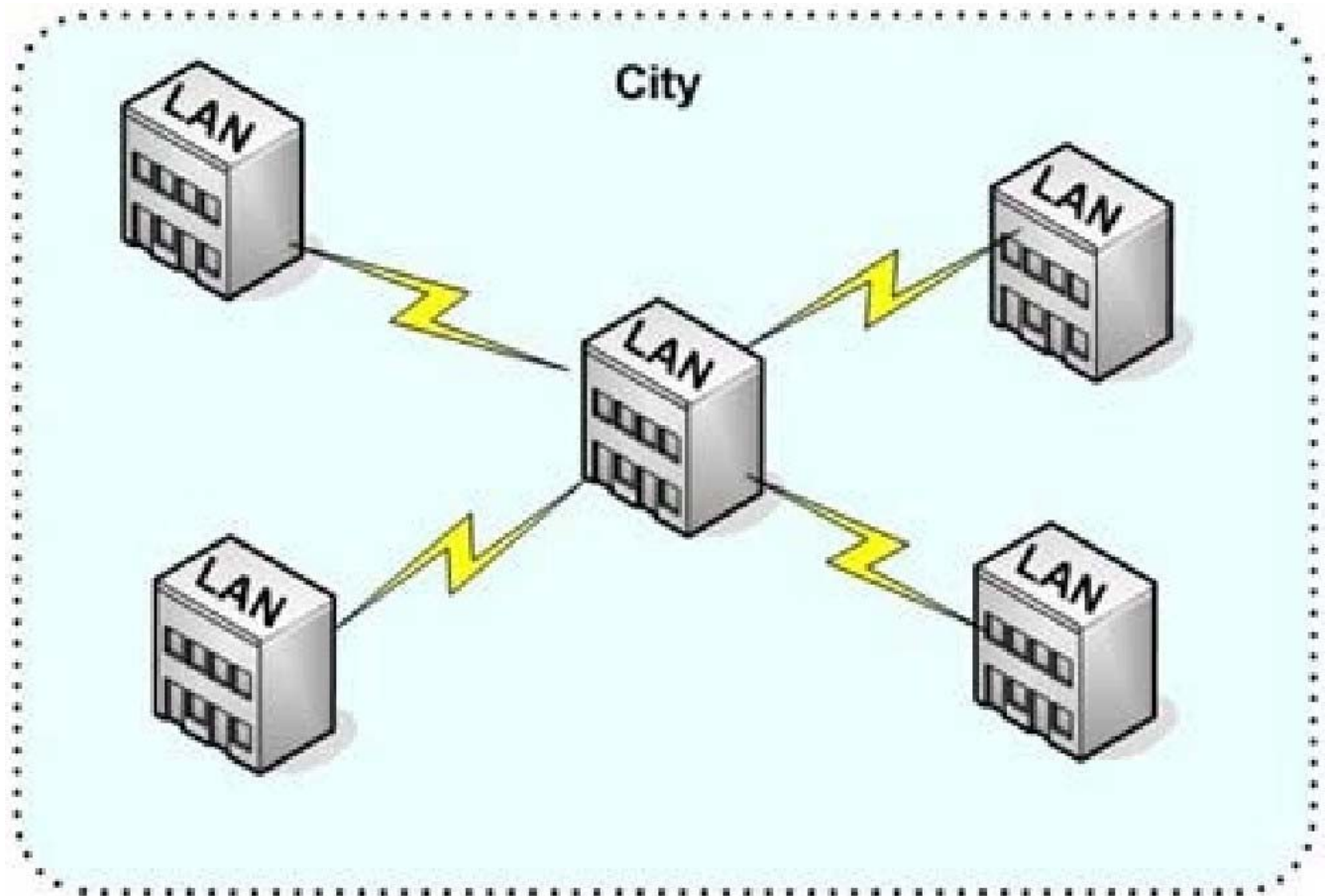
Wide Area Network



Metropolitan Area Network

A metropolitan area network (MAN) is a computer network in which two or more computers or communicating devices or networks which are geographically separated but in same metropolitan city and are connected to each other are said to be connected on MAN. Metropolitan limits are determined by local municipal corporations; the larger the city, the bigger the MAN, the smaller a metro city, smaller the MAN

Metropolitan Area Network

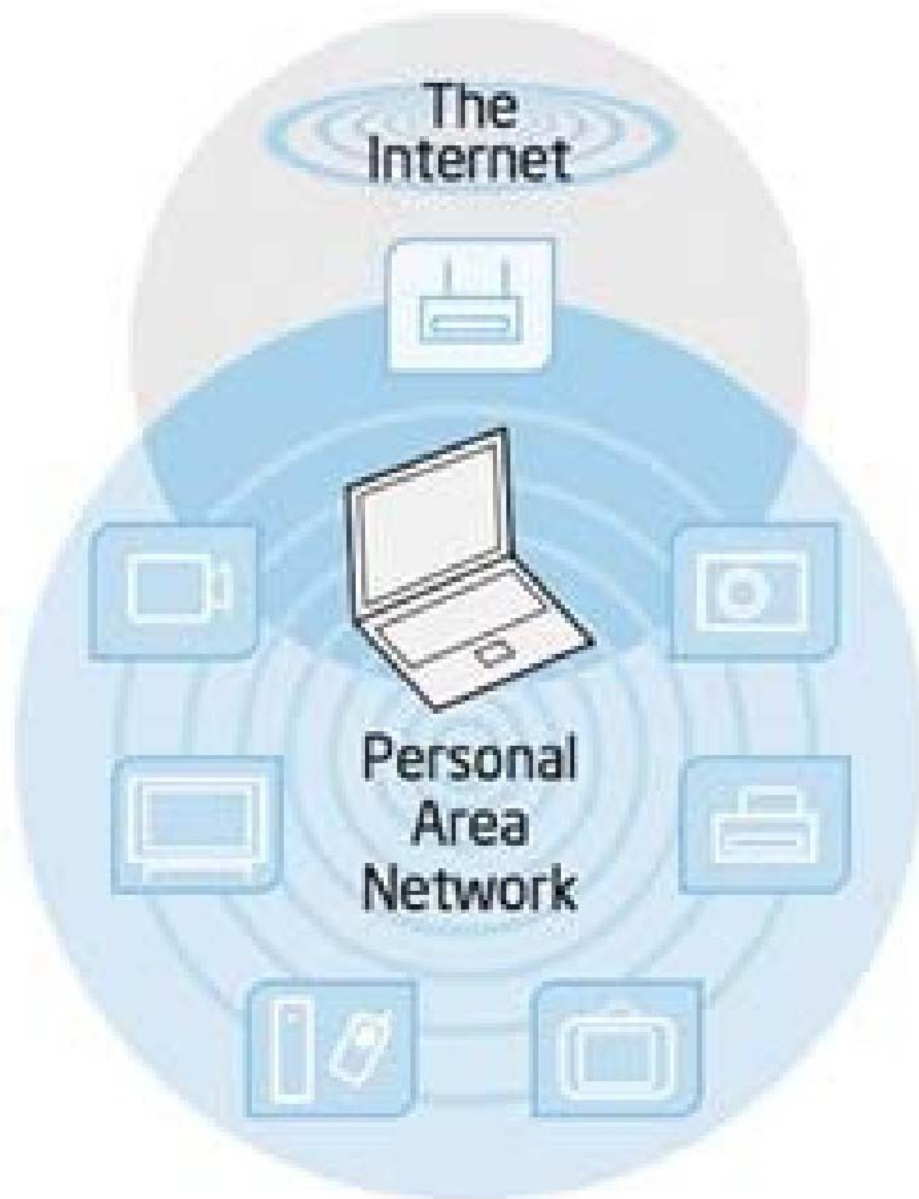


Metropolitan Area Network (MAN)

Personal Area Network

A personal area network (PAN) is a computer network used for data transmission among devices such as computers, telephones and personal digital assistants. PANs can be used for communication among the personal devices themselves (intrapersonal communication), or for connecting to a higher level network and the Internet (an uplink).

Personal Area Network



Storage Area Network

A storage area network (SAN) is a dedicated network that provides access to consolidated, block level data storage. SANs are primarily used to enhance storage devices, such as disk arrays, tape libraries, and optical jukeboxes, accessible to servers so that the devices appear like locally attached devices to the operating system. A SAN typically has its own network of storage devices that are generally not accessible through the local area network (LAN) by other devices.

Storage Area Network

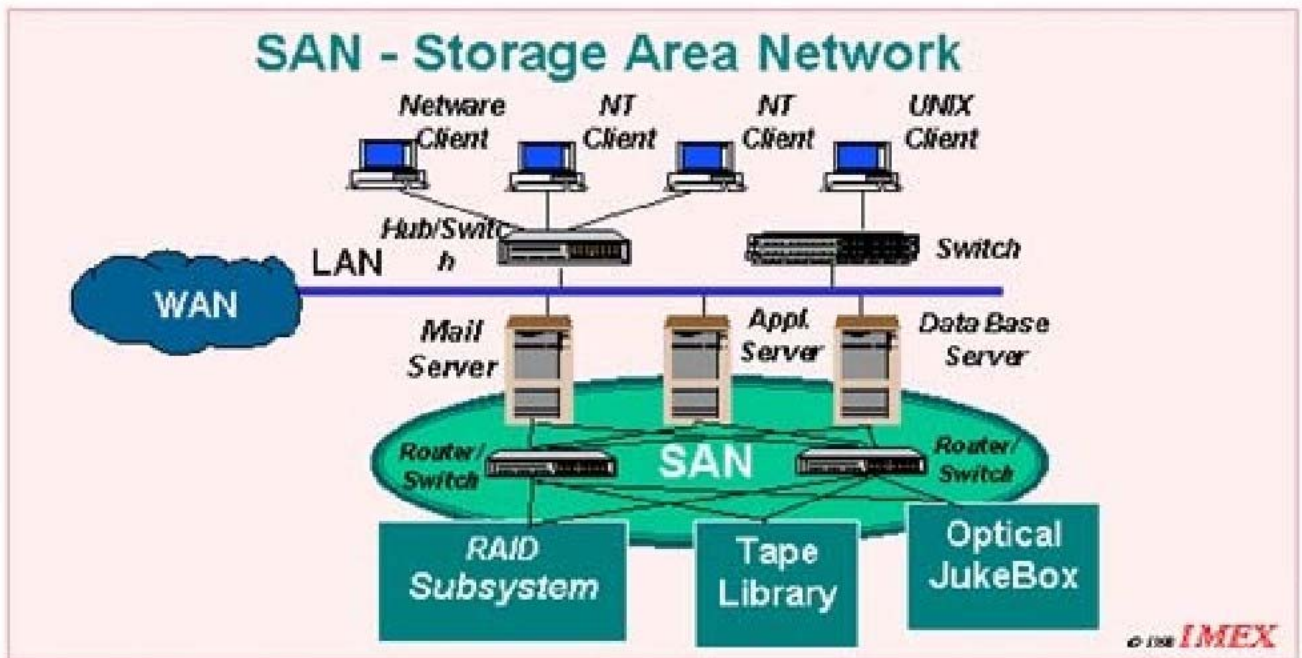


Figure – 3: SAN – Dedicated Storage Area Network dedicated to data movement between servers and storage or between diverse storage devices or between any nodes attached to the SAN.

The following were incorrect answers:

PAN - A personal area network (PAN) is a computer network used for data transmission among devices such as computers, telephones and personal digital assistants. PANs can be used for communication among the personal devices themselves (intrapersonal communication), or for connecting to a higher level network and the Internet (an uplink).

WAN - A wide area network (WAN) is a network that covers a broad area (i.e., any telecommunications network that links across metropolitan, regional, national or international boundaries) using leased telecommunication lines.

SAN - A storage area network (SAN) is a dedicated network that provides access to consolidated, block level data storage. SANs are primarily used to enhance storage devices, such as disk arrays, tape libraries, and optical jukeboxes, accessible to servers so that the devices appear like locally attached devices to the operating system. A SAN typically has its own network of storage devices that are generally not accessible through the local area network (LAN) by other devices. CISA review manual 2014 Page number 258

QUESTION 416

Which of the following type of a computer network covers a broad area such as city, region, nation or international link?

- A. LAN
- B. WAN
- C. SAN
- D. PAN

Correct Answer: B

Explanation

Explanation/Reference:

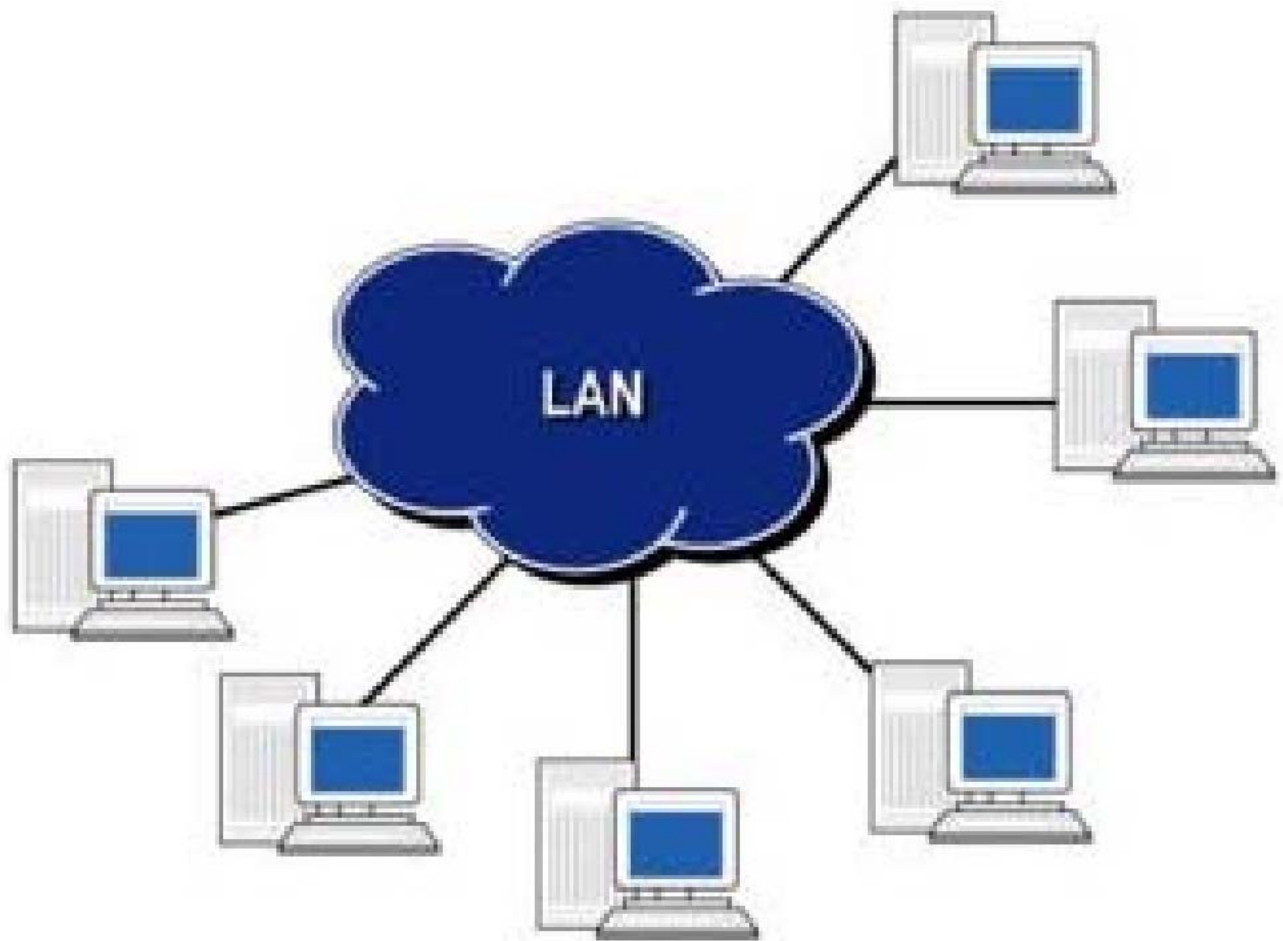
Section: Information System Operations, Maintenance and Support A wide area network (WAN) is a network that covers a broad area (i.e., any telecommunications network that links across metropolitan, regional, national or international boundaries) using leased telecommunication lines.

For your exam you should know below information about computer networks:

Local Area Network (LAN)

A local area network (LAN) is a computer network that interconnects computers within a limited area such as a home, school, computer laboratory, or office building using network media.

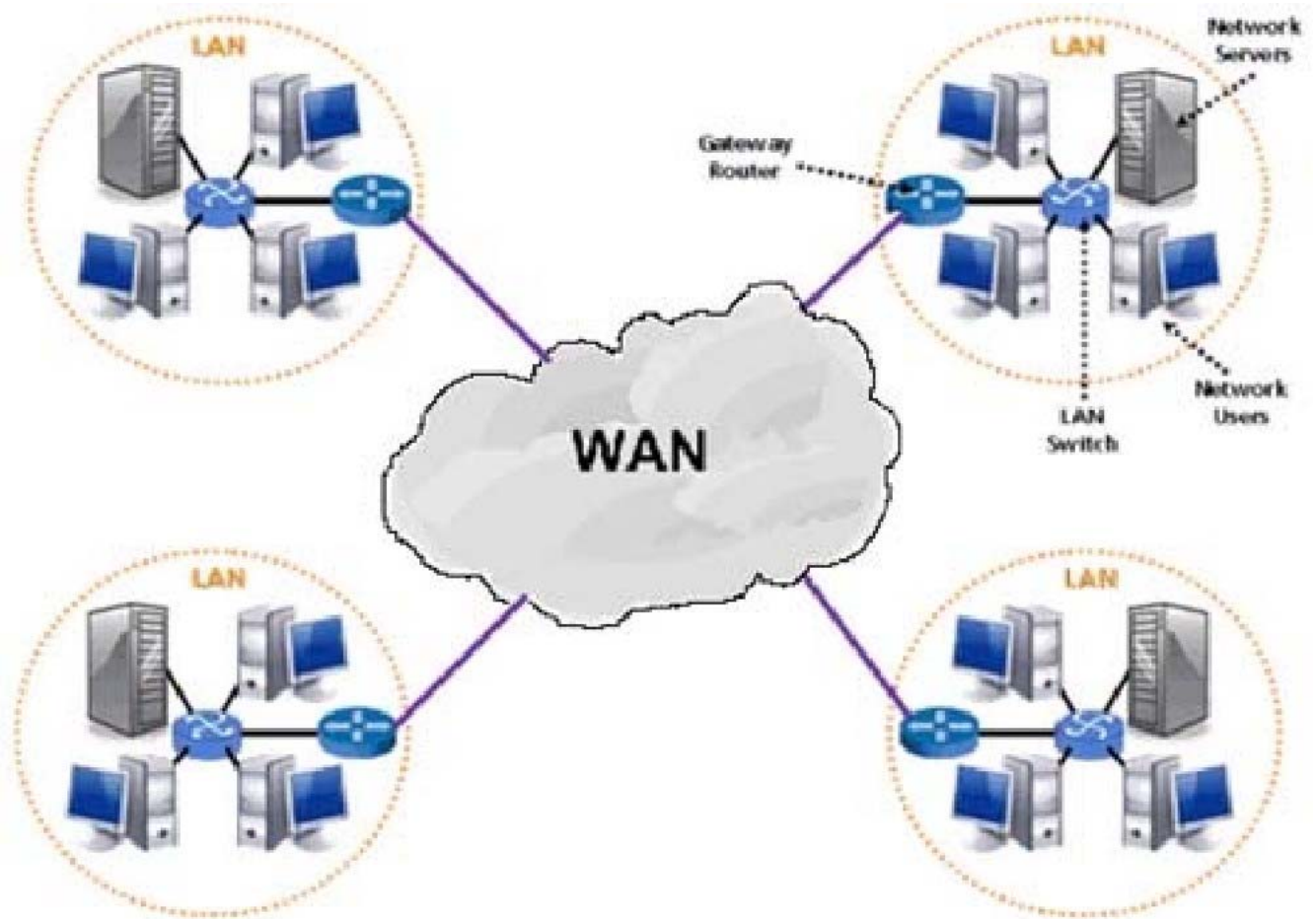
Local Area Network



Wide Area Network

A wide area network (WAN) is a network that covers a broad area (i.e., any telecommunications network that links across metropolitan, regional, national or international boundaries) using leased telecommunication lines.

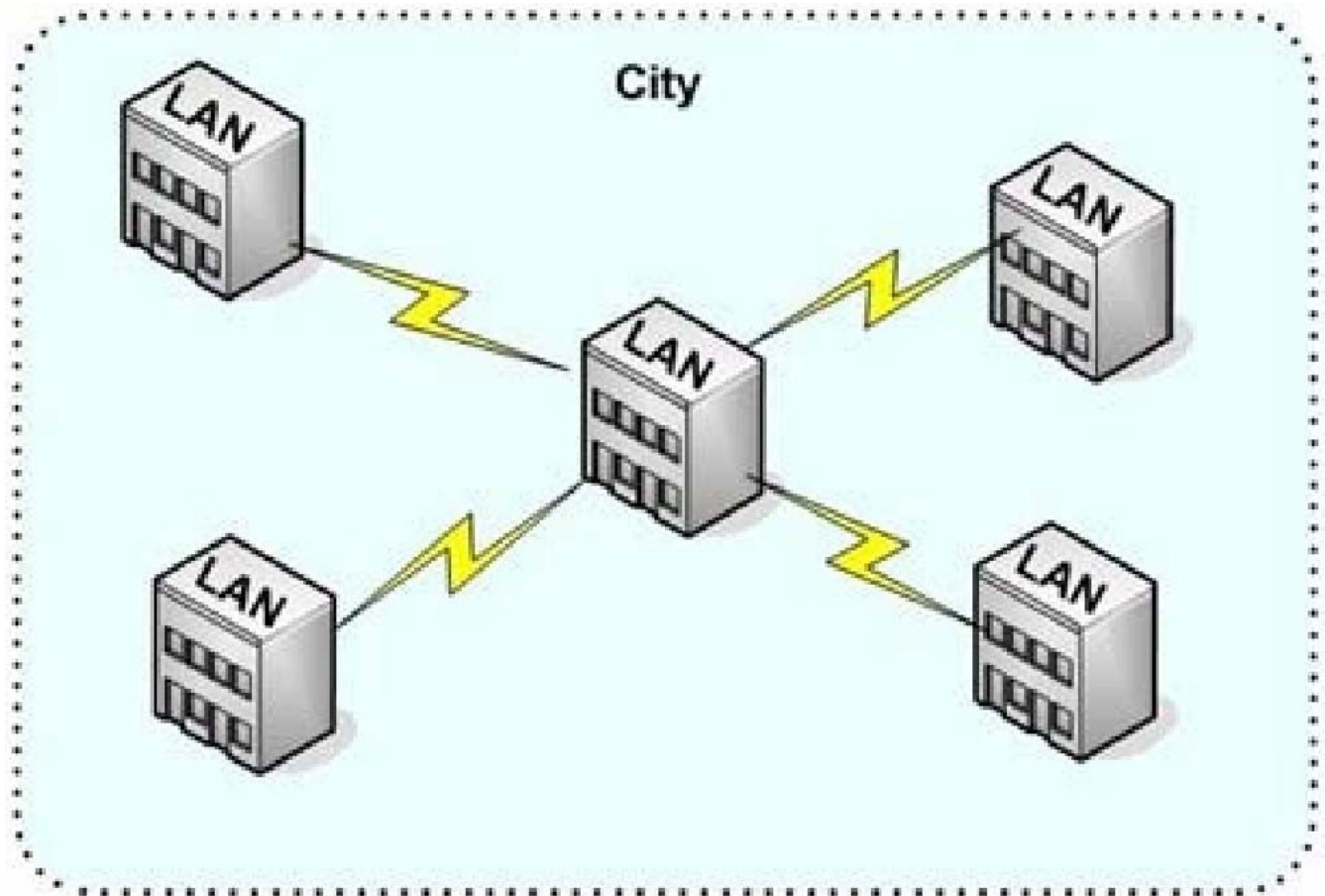
Wide Area Network



Metropolitan Area Network

A metropolitan area network (MAN) is a computer network in which two or more computers or communicating devices or networks which are geographically separated but in same metropolitan city and are connected to each other are said to be connected on MAN. Metropolitan limits are determined by local municipal corporations; the larger the city, the bigger the MAN, the smaller a metro city, smaller the MAN

Metropolitan Area Network

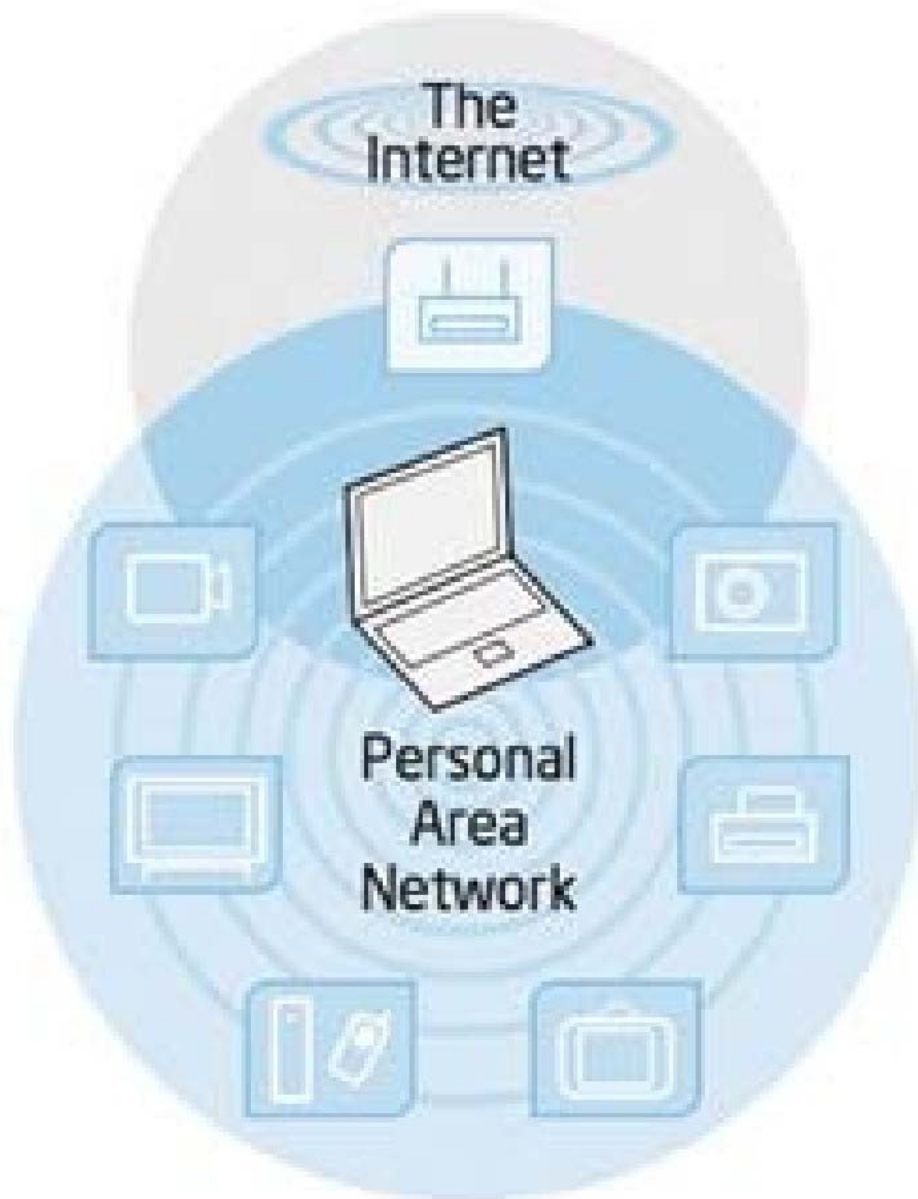


Metropolitan Area Network (MAN)

Personal Area Network

A personal area network (PAN) is a computer network used for data transmission among devices such as computers, telephones and personal digital assistants. PANs can be used for communication among the personal devices themselves (intrapersonal communication), or for connecting to a higher level network and the Internet (an uplink).

Personal Area Network



Storage Area Network

A storage area network (SAN) is a dedicated network that provides access to consolidated, block level data storage. SANs are primarily used to enhance storage devices, such as disk arrays, tape libraries, and optical jukeboxes, accessible to servers so that the devices appear like locally attached devices to the operating system. A SAN typically has its own network of storage devices that are generally not accessible through the local area network (LAN) by other devices.

Storage Area Network

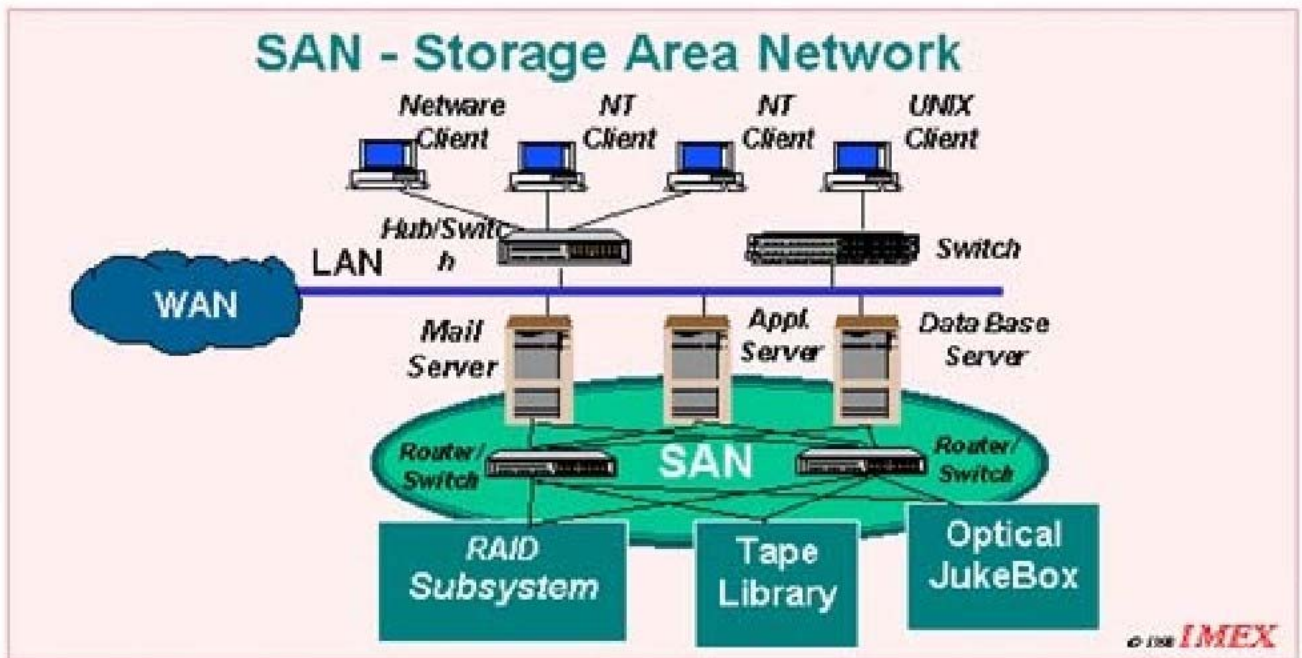


Figure – 3: SAN – Dedicated Storage Area Network dedicated to data movement between servers and storage or between diverse storage devices or between any nodes attached to the SAN.

The following were incorrect answers:

PAN - A personal area network (PAN) is a computer network used for data transmission among devices such as computers, telephones and personal digital assistants. PANs can be used for communication among the personal devices themselves (intrapersonal communication), or for connecting to a higher level network and the Internet (an uplink).

LAN - A local area network (LAN) is a computer network that interconnects computers within a limited area such as a home, school, computer laboratory, or office building using network media.

SAN - A storage area network (SAN) is a dedicated network that provides access to consolidated, block level data storage. SANs are primarily used to enhance storage devices, such as disk arrays, tape libraries, and optical jukeboxes, accessible to servers so that the devices appear like locally attached devices to the operating system. A SAN typically has its own network of storage devices that are generally not accessible through the local area network (LAN) by other devices. CISA review manual 2014 Page number 258

QUESTION 417

Which of the following type of a computer network is a WAN that are limited to a city?

- A. LAN
- B. MAN
- C. SAN
- D. PAN

Correct Answer: B

Explanation

Explanation/Reference:

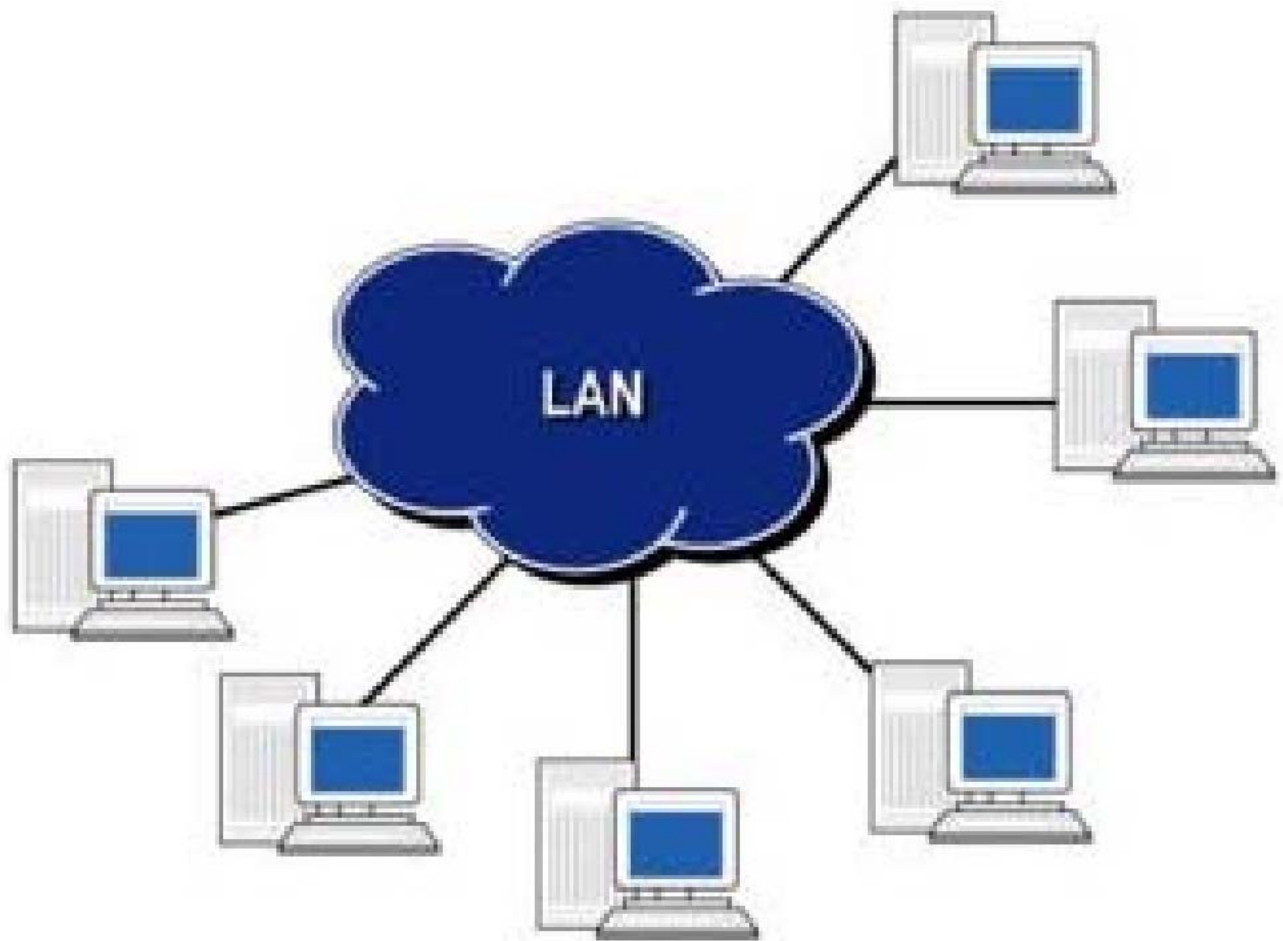
Section: Information System Operations, Maintenance and Support
MAN - A metropolitan area network (MAN) is a computer network in which two or more computers or communicating devices or networks which are geographically separated but in same metropolitan city and are connected to each other are said to be connected on MAN. Metropolitan limits are determined by local municipal corporations; the larger the city, the bigger the MAN, the smaller a metro city, smaller the MAN.

For your exam you should know below information about computer networks:

Local Area Network (LAN)

A local area network (LAN) is a computer network that interconnects computers within a limited area such as a home, school, computer laboratory, or office building using network media.

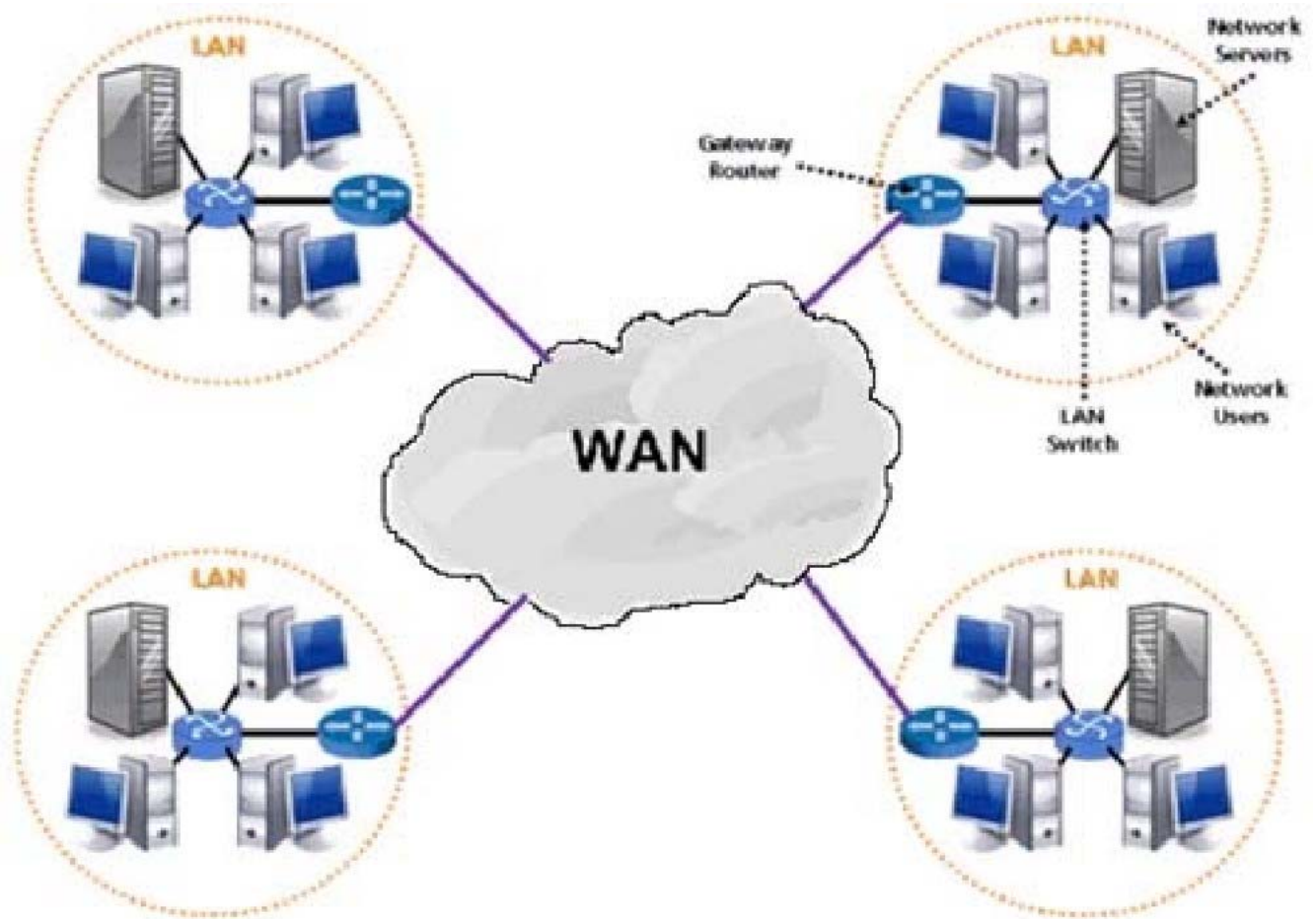
Local Area Network



Wide Area Network

A wide area network (WAN) is a network that covers a broad area (i.e., any telecommunications network that links across metropolitan, regional, national or international boundaries) using leased telecommunication lines.

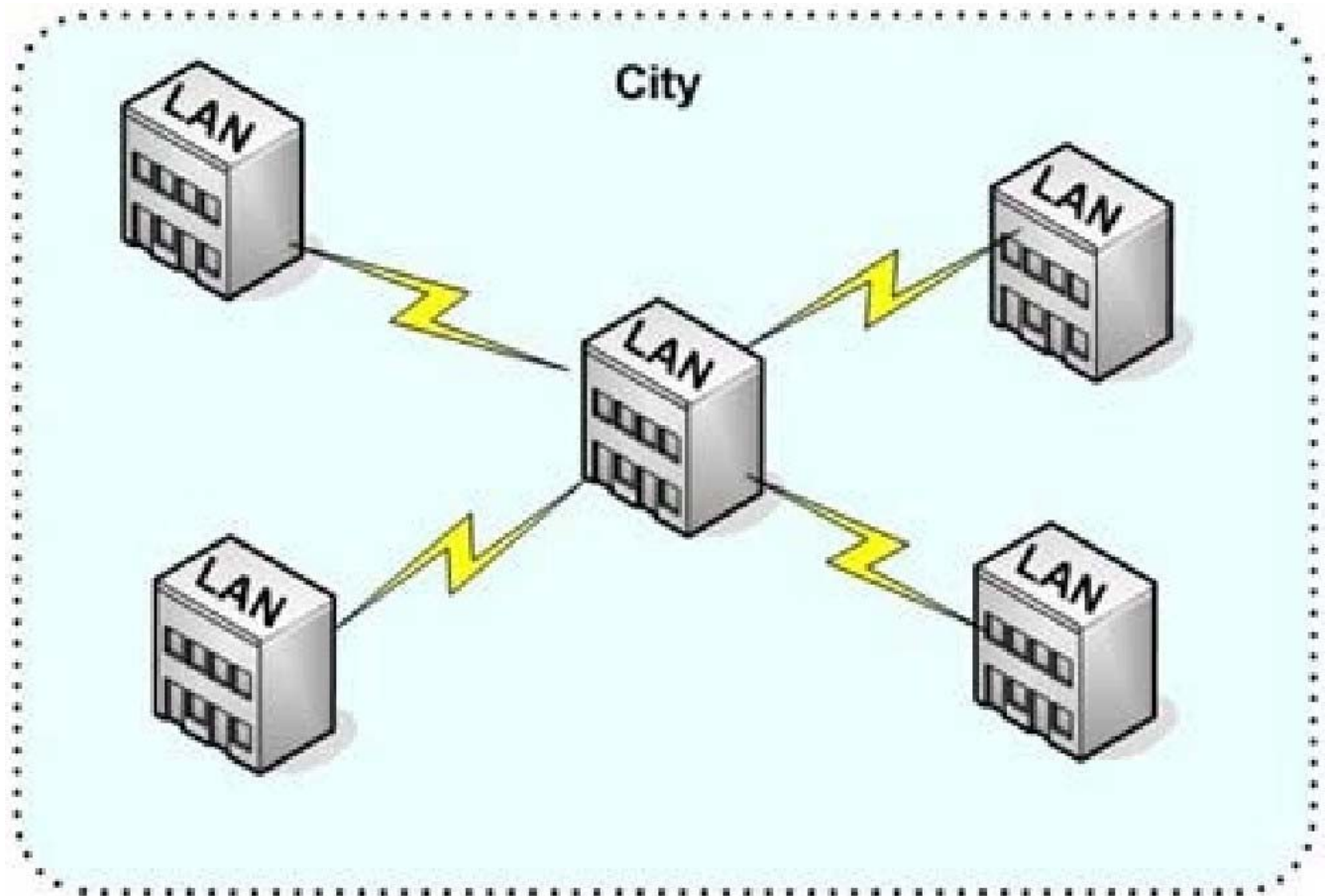
Wide Area Network



Metropolitan Area Network

A metropolitan area network (MAN) is a computer network in which two or more computers or communicating devices or networks which are geographically separated but in same metropolitan city and are connected to each other are said to be connected on MAN. Metropolitan limits are determined by local municipal corporations; the larger the city, the bigger the MAN, the smaller a metro city, smaller the MAN

Metropolitan Area Network

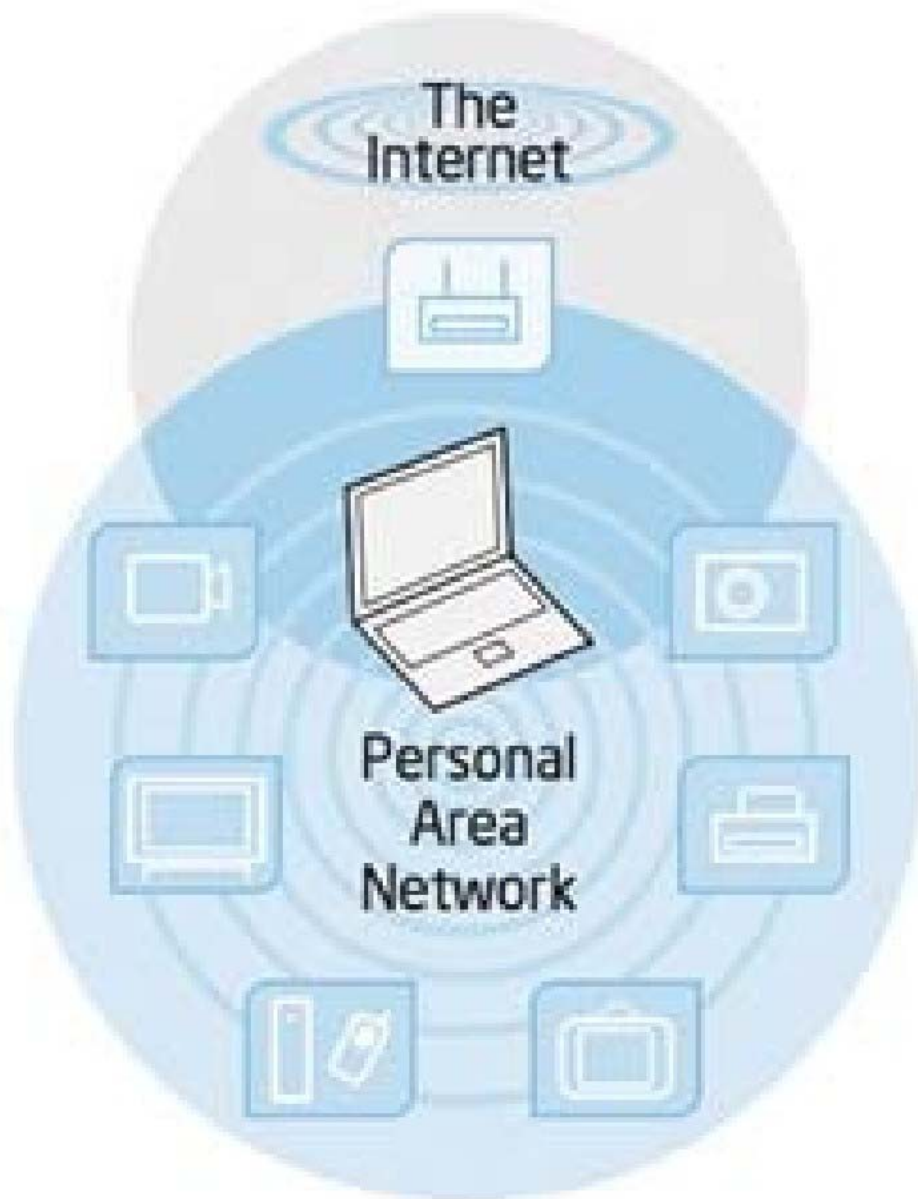


Metropolitan Area Network (MAN)

Personal Area Network

A personal area network (PAN) is a computer network used for data transmission among devices such as computers, telephones and personal digital assistants. PANs can be used for communication among the personal devices themselves (intrapersonal communication), or for connecting to a higher level network and the Internet (an uplink).

Personal Area Network



Storage Area Network

A storage area network (SAN) is a dedicated network that provides access to consolidated, block level data storage. SANs are primarily used to enhance storage devices, such as disk arrays, tape libraries, and optical jukeboxes, accessible to servers so that the devices appear like locally attached devices to the operating system. A SAN typically has its own network of storage devices that are generally not accessible through the local area network (LAN) by other devices.

Storage Area Network

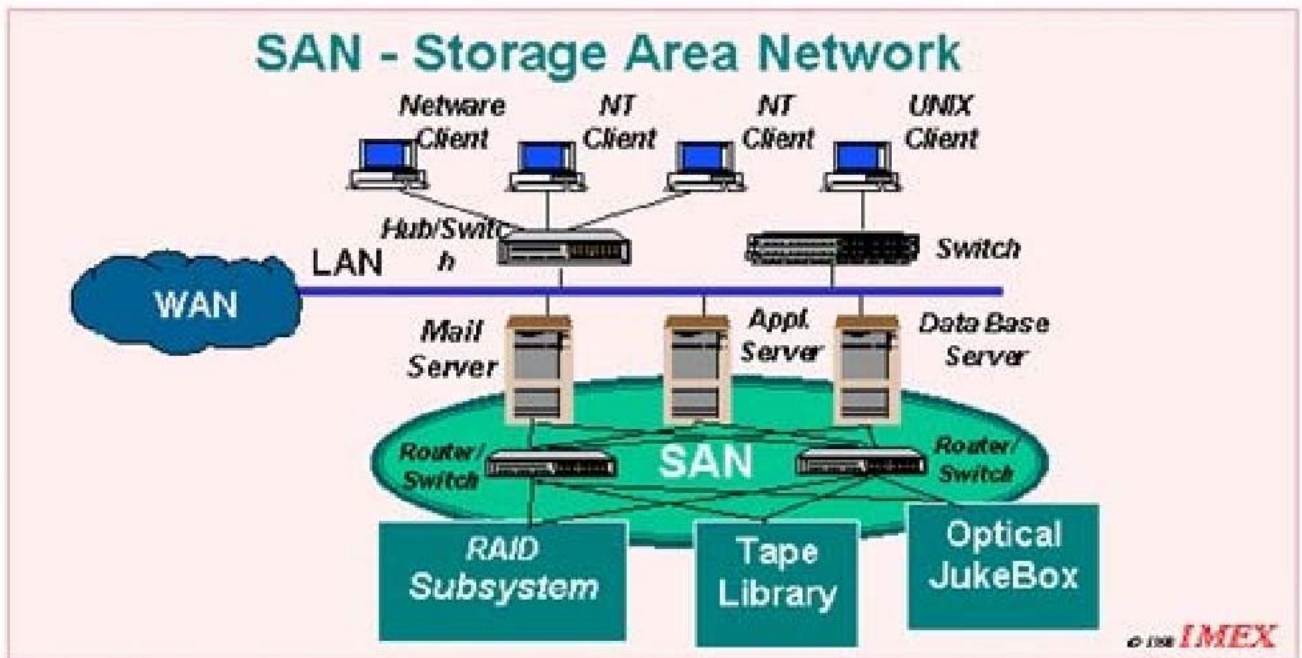


Figure – 3: SAN – Dedicated Storage Area Network dedicated to data movement between servers and storage or between diverse storage devices or between any nodes attached to the SAN.

The following were incorrect answers:

PAN - A personal area network (PAN) is a computer network used for data transmission among devices such as computers, telephones and personal digital assistants. PANs can be used for communication among the personal devices themselves (intrapersonal communication), or for connecting to a higher level network and the Internet (an uplink).

LAN - A local area network (LAN) is a computer network that interconnects computers within a limited area such as a home, school, computer laboratory, or office building using network media.

SAN - A storage area network (SAN) is a dedicated network that provides access to consolidated, block level data storage. SANs are primarily used to enhance storage devices, such as disk arrays, tape libraries, and optical jukeboxes, accessible to servers so that the devices appear like locally attached devices to the operating system. A SAN typically has its own network of storage devices that are generally not accessible through the local area network (LAN) by other devices. CISA review manual 2014 Page number 258

QUESTION 418

Which of the following type of a computer network are variation of LAN and are dedicated to connecting storage devices to servers and other computing devices?

- A. LAN
- B. MAN
- C. SAN
- D. PAN

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support A storage area network (SAN) is a dedicated network that provides access to consolidated, block level data storage. SANs are primarily used to enhance storage devices, such as disk arrays, tape libraries, and optical jukeboxes, accessible to servers so that the devices appear like locally attached devices to the operating

system. A SAN typically has its own network of storage devices that are generally not accessible through the local area network (LAN) by other devices.

For your exam you should know below information about computer networks:

Local Area Network (LAN)

A local area network (LAN) is a computer network that interconnects computers within a limited area such as a home, school, computer laboratory, or office building using network media.

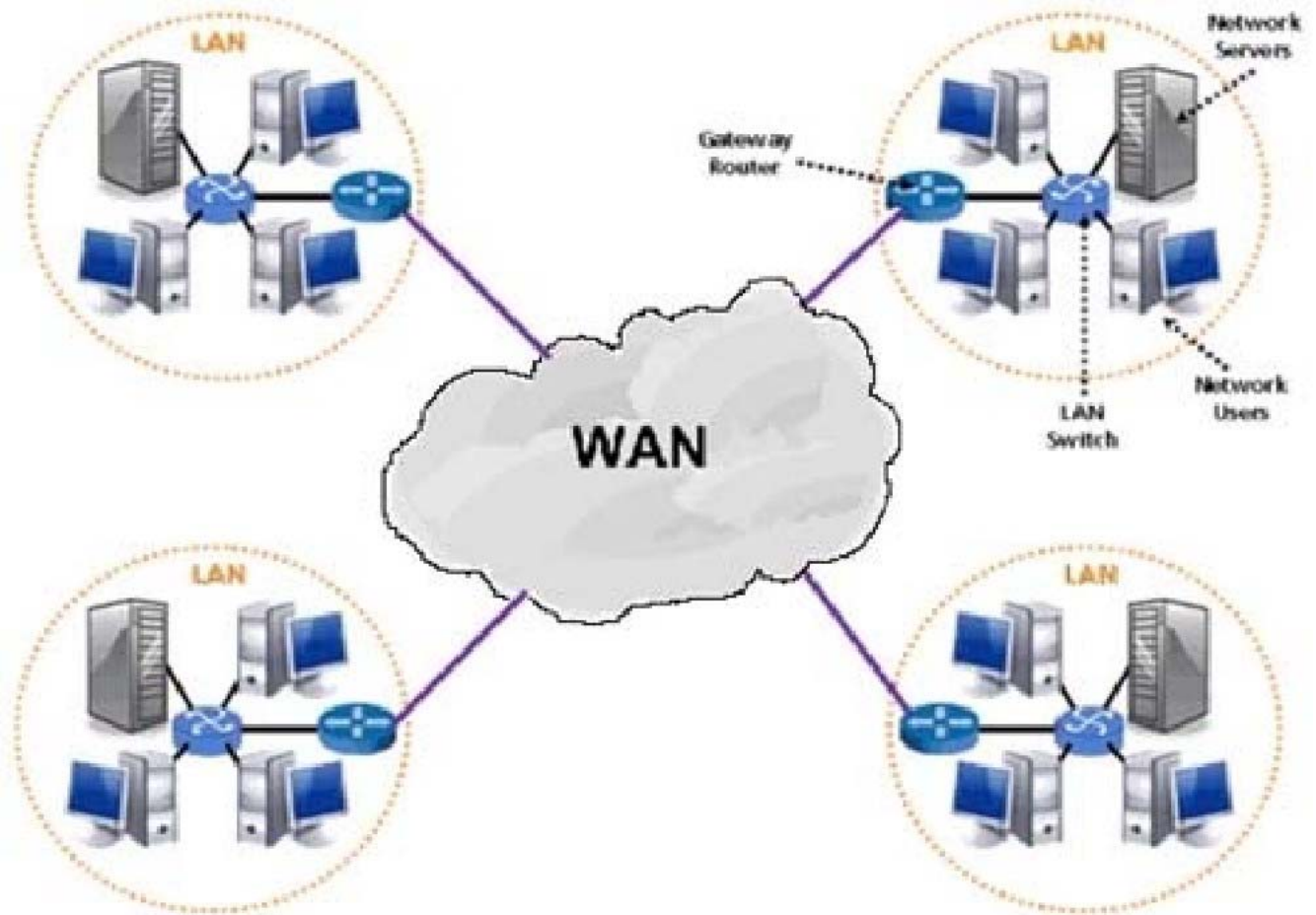
Local Area Network



Wide Area Network

A wide area network (WAN) is a network that covers a broad area (i.e., any telecommunications network that links across metropolitan, regional, national or international boundaries) using leased telecommunication lines.

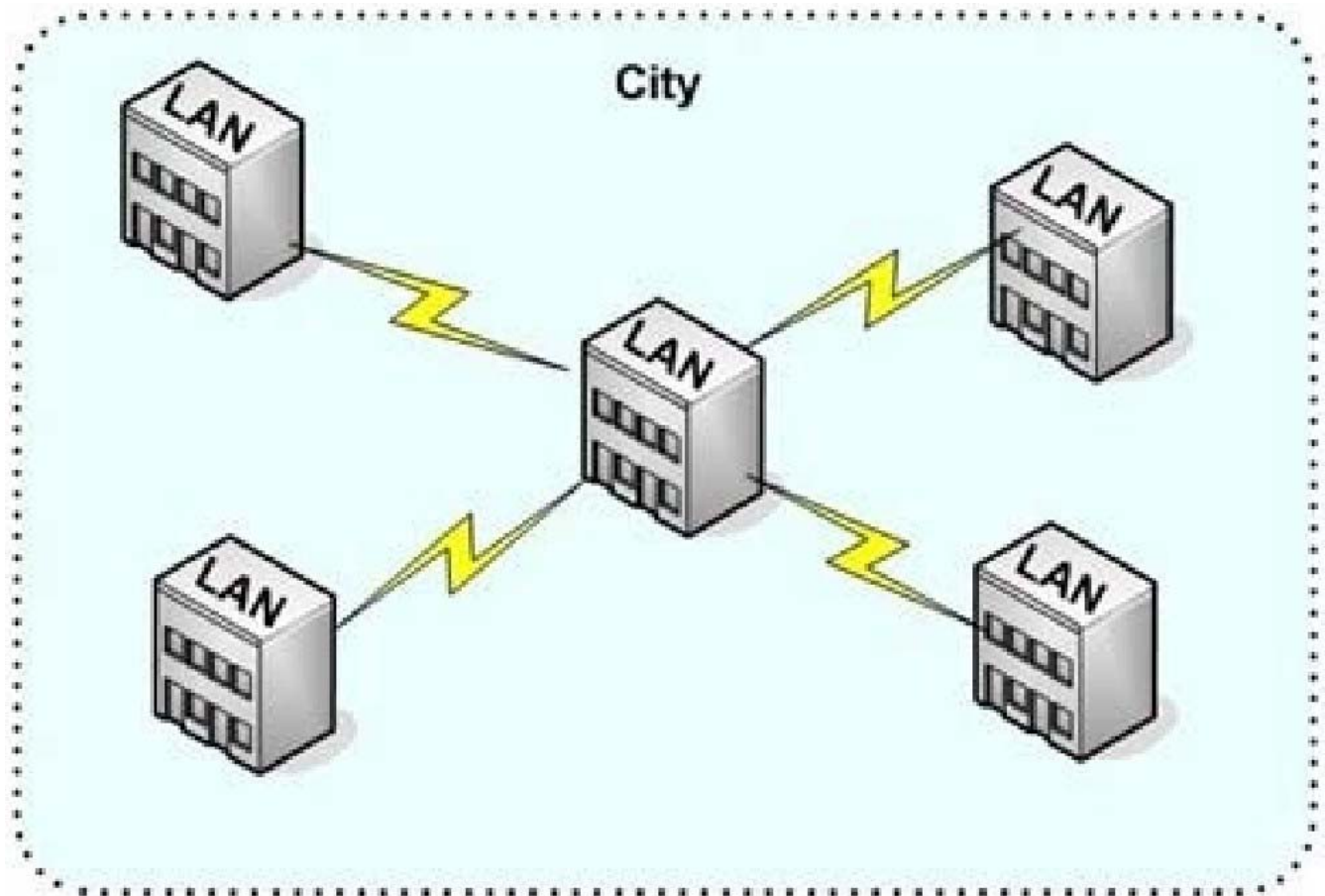
Wide Area Network



Metropolitan Area Network

A metropolitan area network (MAN) is a computer network in which two or more computers or communicating devices or networks which are geographically separated but in same metropolitan city and are connected to each other are said to be connected on MAN. Metropolitan limits are determined by local municipal corporations; the larger the city, the bigger the MAN, the smaller a metro city, smaller the MAN

Metropolitan Area Network

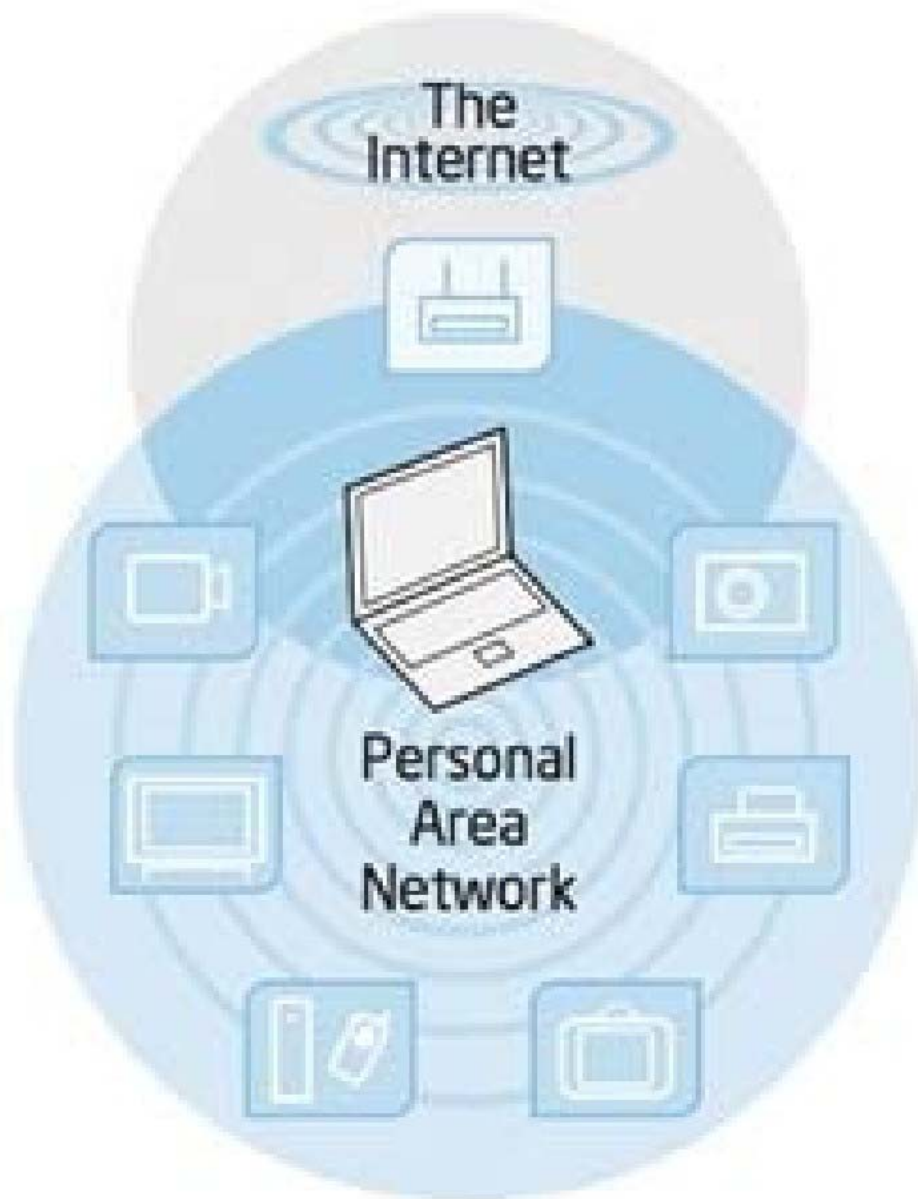


Metropolitan Area Network (MAN)

Personal Area Network

A personal area network (PAN) is a computer network used for data transmission among devices such as computers, telephones and personal digital assistants. PANs can be used for communication among the personal devices themselves (intrapersonal communication), or for connecting to a higher level network and the Internet (an uplink).

Personal Area Network



Storage Area Network

A storage area network (SAN) is a dedicated network that provides access to consolidated, block level data storage. SANs are primarily used to enhance storage devices, such as disk arrays, tape libraries, and optical jukeboxes, accessible to servers so that the devices appear like locally attached devices to the operating system. A SAN typically has its own network of storage devices that are generally not accessible through the local area network (LAN) by other devices.

Storage Area Network

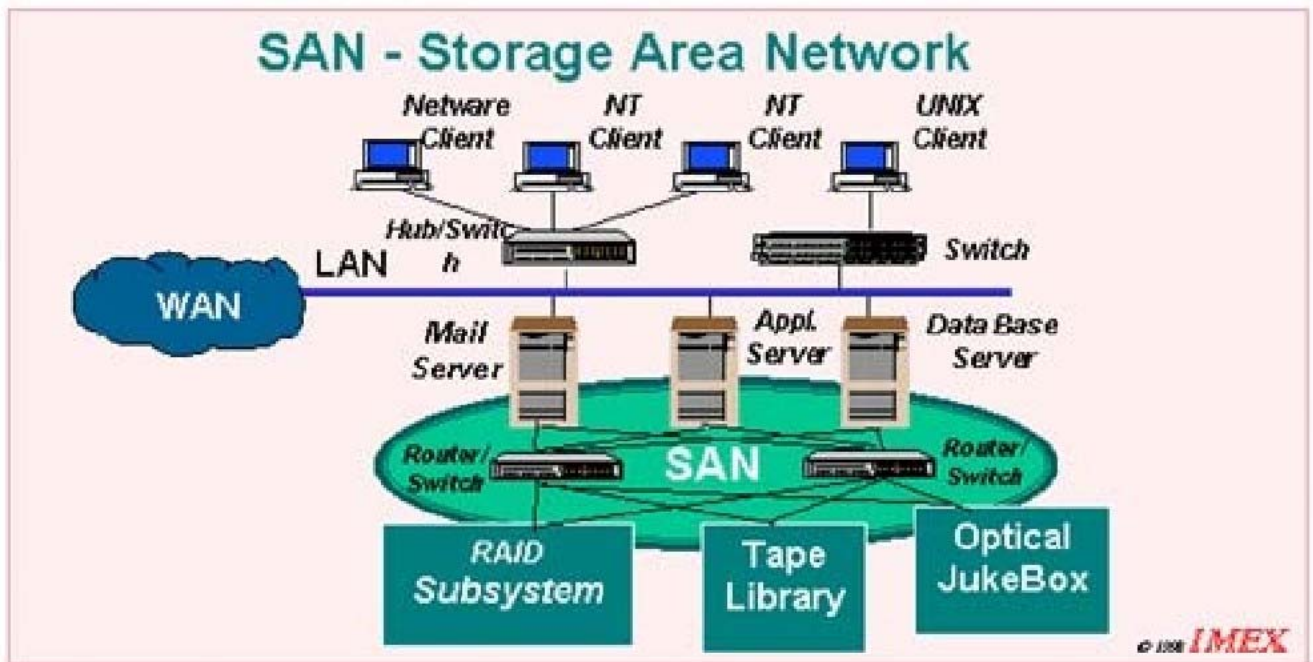


Figure – 3: SAN – Dedicated Storage Area Network dedicated to data movement between servers and storage or between diverse storage devices or between any nodes attached to the SAN.

The following were incorrect answers:

PAN - A personal area network (PAN) is a computer network used for data transmission among devices such as computers, telephones and personal digital assistants. PANs can be used for communication among the personal devices themselves (intrapersonal communication), or for connecting to a higher level network and the Internet (an uplink).

LAN - A local area network (LAN) is a computer network that interconnects computers within a limited area such as a home, school, computer laboratory, or office building using network media.

MAN - A metropolitan area network (MAN) is a computer network in which two or more computers or communicating devices or networks which are geographically separated but in same metropolitan city and are connected to each other are said to be connected on MAN. Metropolitan limits are determined by local municipal corporations; the larger the city, the bigger the MAN, the smaller a metro city, smaller the MAN CISA review manual 2014 Page number 258

QUESTION 419

Which of the following type of network service maps Domain Names to network IP addresses or network IP addresses to Domain Names?

- A. DHCP
- B. DNS
- C. Directory Service
- D. Network Management

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Domain Name System(DNS) - Translates the names of network nodes into network IP address. For your exam you should know below information about network services:

In computer networking, a network service is an application running at the network application layer and above, that provides data storage, manipulation, presentation, communication or other capability which is often implemented using a client-server or peer-to-peer architecture based on application layer network protocols. Each service is usually provided by a server component running on one or more computers (often a dedicated server computer offering multiple services) and accessed via a network by client components running on other devices. However, the client and server components can both be run on the same machine. Clients and servers will often have a user interface, and sometimes other hardware associated with them.

Different types of network services are as follows:

Network File System - Network File System (NFS) is a distributed file system protocol originally developed by Sun Microsystems in 1984, allowing a user on a client computer to access files over a network much like local storage is accessed.

Remote Access Service - Remote Access Services (RAS) refers to any combination of hardware and software to enable the remote access tools or information that typically reside on a network of IT devices. Directory Services - A directory service is the software system that stores, organizes and provides access to information in a directory. In software engineering, a directory is a map between names and values. It allows the lookup of values given a name, similar to a dictionary. As a word in a dictionary may have multiple definitions, in a directory, a name may be associated with multiple, different pieces of information. Likewise, as a word may have different parts of speech and different definitions, a name in a directory may have many different types of data.

Network Management - In computer networks, network management refers to the activities, methods, procedures, and tools that pertain to the operation, administration, maintenance, and provisioning of networked systems. Network management is essential to command and control practices and is generally carried out of a network operations center.

Dynamic Host Configuration Protocol (DHCP) - The Dynamic Host Configuration Protocol (DHCP) is a standardized networking protocol used on Internet Protocol (IP) networks for dynamically distributing network configuration parameters, such as IP addresses for interfaces and services. With DHCP, computers request IP addresses and networking parameters automatically from a DHCP server, reducing the need for a network administrator or a user to configure these settings manually.

Email service - Provides the ability, through a terminal or PC connected to a communication network, to send an entrusted message to another individual or group of people. Print Services - Provide the ability, typically through a print server on a network, to manage and execute print request services from other devices on the network

Domain Name System(DNS) - Translates the names of network nodes into network IP address.

The following were incorrect answers:

Dynamic Host Configuration Protocol (DHCP) - The Dynamic Host Configuration Protocol (DHCP) is a standardized networking protocol used on Internet Protocol (IP) networks for dynamically distributing network configuration parameters, such as IP addresses for interfaces and services. With DHCP, computers request IP addresses and networking parameters automatically from a DHCP server, reducing the need for a network administrator or a user to configure these settings manually.

Directory Services - A directory service is the software system that stores, organizes and provides access to information in a directory. In software engineering, a directory is a map between names and values. It allows the lookup of values given a name, similar to a dictionary. As a word in a dictionary may have multiple definitions, in a directory, a name may be associated with multiple, different pieces of information. Likewise, as a word may have different parts of speech and different definitions, a name in a directory may have many different types of data.

Network Management - In computer networks, network management refers to the activities, methods, procedures, and tools that pertain to the operation, administration, maintenance, and provisioning of networked systems. Network management is essential to command and control practices and is generally carried out of a network operations center.

CISA review manual 2014 Page number 258

QUESTION 420

Which of the following type of network service stores information about the various resources in a central database on a network and help network devices locate services?

- A. DHCP
- B. DNS
- C. Directory Service
- D. Network Management

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support A directory service is the software system that stores, organizes and provides access to information in a directory. In software engineering, a directory is a map between names and values. It allows the lookup of values given a name, similar to a dictionary. As a word in a dictionary may have multiple definitions, in a directory, a name may be associated with multiple, different pieces of information. Likewise, as a word may have different parts of speech and different definitions, a name in a directory may have many different types of data.

For your exam you should know below information about network services:

In computer networking, a network service is an application running at the network application layer and above, that provides data storage, manipulation, presentation, communication or other capability which is often implemented using a client-server or peer-to-peer architecture based on application layer network protocols. Each service is usually provided by a server component running on one or more computers (often a dedicated server computer offering multiple services) and accessed via a network by client components running on other devices. However, the client and server components can both be run on the same machine. Clients and servers will often have a user interface, and sometimes other hardware associated with them.

Different types of network services are as follows:

Network File System - Network File System (NFS) is a distributed file system protocol originally developed by Sun Microsystems in 1984, allowing a user on a client computer to access files over a network much like local storage is accessed.

Remote Access Service - Remote Access Services (RAS) refers to any combination of hardware and software to enable the remote access tools or information that typically reside on a network of IT devices. Directory Services - A directory service is the software system that stores, organizes and provides access to information in a directory. In software engineering, a directory is a map between names and values. It allows the lookup of values given a name, similar to a dictionary. As a word in a dictionary may have multiple definitions, in a directory, a name may be associated with multiple, different pieces of information. Likewise, as a word may have different parts of speech and different definitions, a name in a directory may have many different types of data.

Network Management - In computer networks, network management refers to the activities, methods, procedures, and tools that pertain to the operation, administration, maintenance, and provisioning of networked systems. Network management is essential to command and control practices and is generally carried out of a network operations center.

Dynamic Host Configuration Protocol (DHCP) - The Dynamic Host Configuration Protocol (DHCP) is a standardized networking protocol used on Internet Protocol (IP) networks for dynamically distributing network configuration parameters, such as IP addresses for interfaces and services. With DHCP, computers request IP addresses and networking parameters automatically from a DHCP server, reducing the need for a network administrator or a user to configure these settings manually.

Email service - Provides the ability, through a terminal or PC connected to a communication network, to send an entrusted message to another individual or group of people. Print Services - Provide the ability, typically through a print server on a network, to manage and execute print request services from other devices on the network

Domain Name System(DNS) - Translates the names of network nodes into network IP address.

The following were incorrect answers:

Dynamic Host Configuration Protocol (DHCP) - The Dynamic Host Configuration Protocol (DHCP) is a standardized networking protocol used on Internet Protocol (IP) networks for dynamically distributing network configuration parameters, such as IP addresses for interfaces and services. With DHCP, computers request IP addresses and networking parameters automatically from a DHCP server, reducing the need for a network administrator or a user to configure these settings manually.

Domain Name System(DNS) - Translates the names of network nodes into network IP address. Network Management - In computer networks, network management refers to the activities, methods, procedures, and tools that pertain to the operation, administration, maintenance, and provisioning of networked systems. Network management is essential to command and control practices and is generally carried out of a network operations center.

CISA review manual 2014 Page number 258

QUESTION 421

Which of the following type of network service is used by network computer to obtain an IP addresses and other parameters such as default gateway, subnet mask?

- A. DHCP
- B. DNS
- C. Directory Service
- D. Network Management

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Dynamic Host Configuration Protocol (DHCP) - The Dynamic Host Configuration Protocol (DHCP) is a standardized networking protocol used on Internet Protocol (IP) networks for dynamically distributing network configuration parameters, such as IP addresses for interfaces and services. With DHCP, computers request IP addresses and networking parameters automatically from a DHCP server, reducing the need for a network administrator or a user to configure these settings manually.

For your exam you should know below information about network services:

In computer networking, a network service is an application running at the network application layer and above, that provides data storage, manipulation,

presentation, communication or other capability which is often implemented using a client-server or peer-to-peer architecture based on application layer network protocols. Each service is usually provided by a server component running on one or more computers (often a dedicated server computer offering multiple services) and accessed via a network by client components running on other devices. However, the client and server components can both be run on the same machine. Clients and servers will often have a user interface, and sometimes other hardware associated with them.

Different types of network services are as follows:

Network File System - Network File System (NFS) is a distributed file system protocol originally developed by Sun Microsystems in 1984, allowing a user on a client computer to access files over a network much like local storage is accessed.

Remote Access Service - Remote Access Services (RAS) refers to any combination of hardware and software to enable the remote access tools or information that typically reside on a network of IT devices. **Directory Services** - A directory service is the software system that stores, organizes and provides access to information in a directory. In software engineering, a directory is a map between names and values. It allows the lookup of values given a name, similar to a dictionary. As a word in a dictionary may have multiple definitions, in a directory, a name may be associated with multiple, different pieces of information. Likewise, as a word may have different parts of speech and different definitions, a name in a directory may have many different types of data.

Network Management - In computer networks, network management refers to the activities, methods, procedures, and tools that pertain to the operation, administration, maintenance, and provisioning of networked systems. Network management is essential to command and control practices and is generally carried out of a network operations center.

Dynamic Host Configuration Protocol (DHCP) - The Dynamic Host Configuration Protocol (DHCP) is a standardized networking protocol used on Internet Protocol (IP) networks for dynamically distributing network configuration parameters, such as IP addresses for interfaces and services. With DHCP, computers request IP addresses and networking parameters automatically from a DHCP server, reducing the need for a network administrator or a user to configure these settings manually.

Email service - Provides the ability, through a terminal or PC connected to a communication network, to send an entrusted message to another individual or group of people. **Print Services** - Provide the ability, typically through a print server on a network, to manage and execute print request services from other devices on the network.

Domain Name System(DNS) - Translates the names of network nodes into network IP address.

The following were incorrect answers:

Directory Service - A directory service is the software system that stores, organizes and provides access to information in a directory. In software engineering, a directory is a map between names and values. It allows the lookup of values given a name, similar to a dictionary. As a word in a dictionary may have multiple definitions, in a directory, a name may be associated with multiple, different pieces of information. Likewise, as a word may have different parts of speech and different definitions, a name in a directory may have many different types of data.

Domain Name System(DNS) - Translates the names of network nodes into network IP address. **Network Management** - In computer networks, network management refers to the activities, methods, procedures, and tools that pertain to the operation, administration, maintenance, and provisioning of networked systems. Network management is essential to command and control practices and is generally carried out of a network operations center.

CISA review manual 2014 Page number 258

QUESTION 422

Which of the following layer of the OSI model provides a standard interface for applications to communicate with devices on a network?

- A. Application layer
- B. Presentation layer
- C. Session layer
- D. Transport layer

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The application layer serves as the window for users and application processes to access network services.

This layer contains a variety of commonly needed functions:

- Resource sharing and device redirection
- Remote file access
- Remote printer access
- Inter-process communication
- Network management
- Directory services
- Electronic messaging (such as mail)
- Network virtual terminals

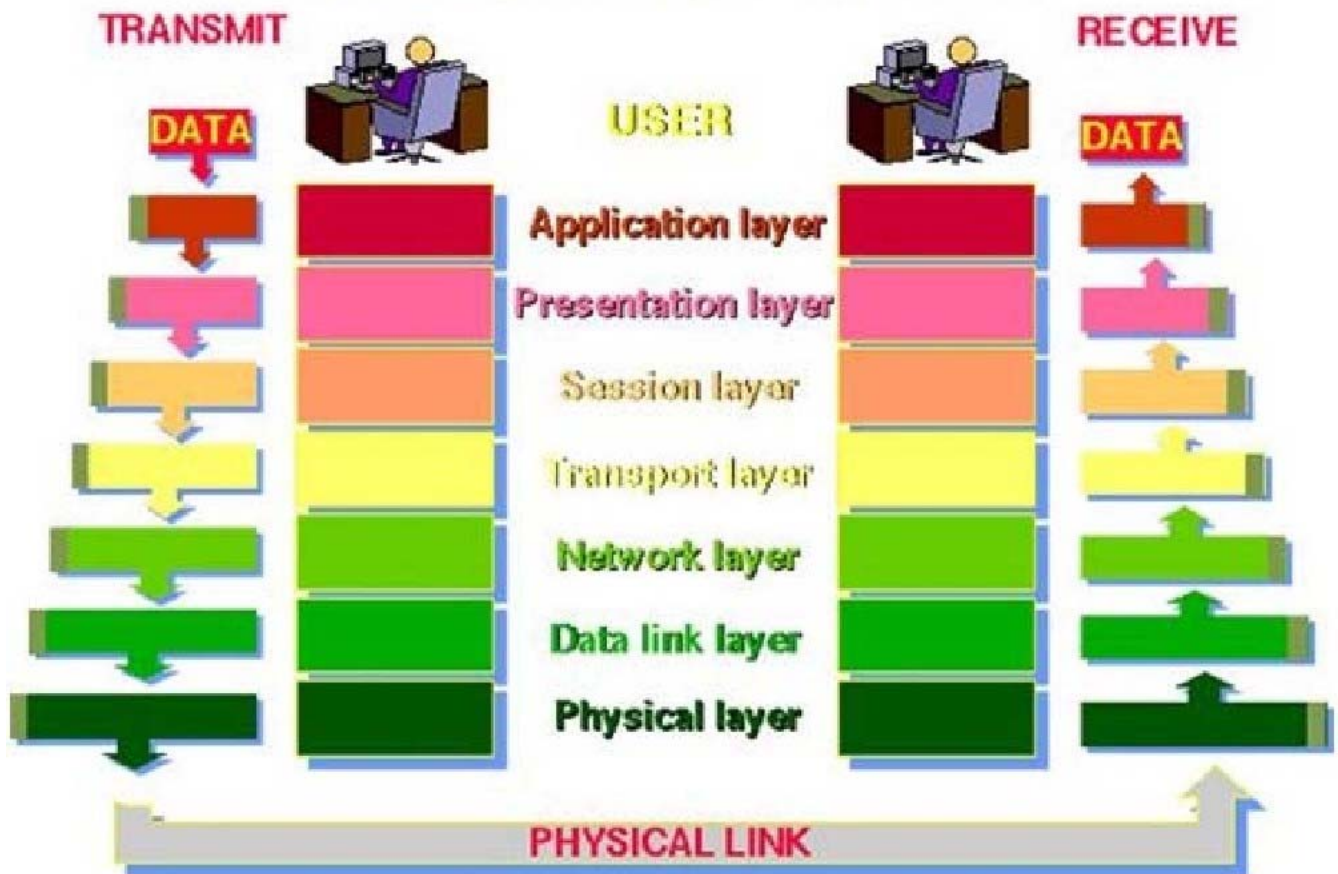
For your exam you should know below information about OSI model:

The Open Systems Interconnection model (OSI) is a conceptual model that characterizes and standardizes the internal functions of a communication system by partitioning it into abstraction layers. The model is a product of the Open Systems Interconnection project at the International Organization for Standardization (ISO), maintained by the identification ISO/IEC 7498-1.

The model groups communication functions into seven logical layers. A layer serves the layer above it and is served by the layer below it. For example, a layer that provides error-free communications across a network provides the path needed by applications above it, while it calls the next lower layer to send and receive packets that make up the contents of that path. Two instances at one layer are connected by a horizontal.

OSI Model

THE 7 LAYERS OF OSI



PHYSICAL LAYER

The physical layer, the lowest layer of the OSI model, is concerned with the transmission and reception of the unstructured raw bit stream over a physical medium. It describes the electrical/optical, mechanical, and functional interfaces to the physical medium, and carries the signals for all of the higher layers. It provides:

Data encoding: modifies the simple digital signal pattern (1s and 0s) used by the PC to better accommodate the characteristics of the physical medium, and to aid in bit and frame synchronization. It determines:

- What signal state represents a binary 1
- How the receiving station knows when a "bit-time" starts
- How the receiving station delimits a frame

DATA LINK LAYER

The data link layer provides error-free transfer of data frames from one node to another over the physical layer, allowing layers above it to assume virtually error-free transmission over the link. To do this, the data link layer provides:

- Link establishment and termination: establishes and terminates the logical link between two nodes.
- Frame traffic control: tells the transmitting node to "back-off" when no frame buffers are available.
- Frame sequencing: transmits/receives frames sequentially.
- Frame acknowledgment: provides/expects frame acknowledgments. Detects and recovers from errors that occur in the physical layer by retransmitting non-acknowledged frames and handling duplicate frame receipt.
- Frame delimiting: creates and recognizes frame boundaries.
- Frame error checking: checks received frames for integrity.
- Media access management: determines when the node "has the right" to use the physical medium.

NETWORK LAYER

The network layer controls the operation of the subnet, deciding which physical path the data should take based on network conditions, priority of service, and other factors. It provides:

- Routing: routes frames among networks.
- Subnet traffic control: routers (network layer intermediate systems) can instruct a sending station to "throttle back" its frame transmission when the router's buffer fills up.
- Frame fragmentation: if it determines that a downstream router's maximum transmission unit (MTU) size is less than the frame size, a router can fragment a frame for transmission and re-assembly at the destination station.
- Logical-physical address mapping: translates logical addresses, or names, into physical addresses.
- Subnet usage accounting: has accounting functions to keep track of frames forwarded by subnet intermediate systems, to produce billing information.

Communications Subnet

The network layer software must build headers so that the network layer software residing in the subnet intermediate systems can recognize them and use them to route data to the destination address.

This layer relieves the upper layers of the need to know anything about the data transmission and intermediate

switching technologies used to connect systems. It establishes, maintains and terminates connections across the intervening communications facility (one or several intermediate systems in the communication subnet).

In the network layer and the layers below, peer protocols exist between a node and its immediate neighbor, but the neighbor may be a node through which data is

routed, not the destination station. The source and destination stations may be separated by many intermediate systems.

TRANSPORT LAYER

The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

The size and complexity of a transport protocol depends on the type of service it can get from the network layer. For a reliable network layer with virtual circuit capability, a minimal transport layer is required. If the network layer is unreliable and/or only supports datagram's, the transport protocol should include extensive error detection and recovery.

The transport layer provides:

Message segmentation: accepts a message from the (session) layer above it, splits the message into smaller units (if not already small enough), and passes the smaller units down to the network layer. The transport layer at the destination station reassembles the message.

Message acknowledgment: provides reliable end-to-end message delivery with acknowledgments. Message traffic control: tells the transmitting station to "back-off" when no message buffers are available. Session multiplexing: multiplexes several message streams, or sessions onto one logical link and keeps track of which messages belong to which sessions (see session layer).

Typically, the transport layer can accept relatively large messages, but there are strict message size limits imposed by the network (or lower) layer. Consequently, the transport layer must break up the messages into smaller units, or frames, pretending a header to each frame.

The transport layer header information must then include control information, such as message start and message end flags, to enable the transport layer on the other end to recognize message boundaries. In addition, if the lower layers do not maintain sequence, the transport header must contain sequence information to enable the transport layer on the receiving end to get the pieces back together in the right order before handing the received message up to the layer above.

End-to-end layers

Unlike the lower "subnet" layers whose protocol is between immediately adjacent nodes, the transport layer and the layers above are true "source to destination" or end-to-end layers, and are not concerned with the details of the underlying communications facility. Transport layer software (and software above it) on the source station carries on a conversation with similar software on the destination station by using message headers and control messages.

SESSION LAYER

The session layer allows session establishment between processes running on different stations. It provides:

Session establishment, maintenance and termination: allows two application processes on different machines to establish, use and terminate a connection, called a session. Session support: performs the functions that allow these processes to communicate over the network, performing security, name recognition, logging, and so on.

PRESENTATION LAYER

The presentation layer formats the data to be presented to the application layer. It can be viewed as the translator for the network. This layer may translate data from a format used by the application layer into a common format at the sending station, then translate the common format to a format known to the application layer at the receiving station.

The presentation layer provides:

Character code translation: for example, ASCII to EBCDIC.

Data conversion: bit order, CR-CR/LF, integer-floating point, and so on.

Data compression: reduces the number of bits that need to be transmitted on the network. Data encryption: encrypt data for security purposes. For example, password encryption.

APPLICATION LAYER

The application layer serves as the window for users and application processes to access network services.

This layer contains a variety of commonly needed functions:

Resource sharing and device redirection

Remote file access

Remote printer access

Inter-process communication

Network management

Directory services

Electronic messaging (such as mail)

Network virtual terminals

The following were incorrect answers:

Presentation layer - The presentation layer formats the data to be presented to the application layer. It can be viewed as the translator for the network. This layer may translate data from a format used by the application layer into a common format at the sending station, then translate the common format to a format known to the application layer at the receiving station.

Session layer - The session layer allows session establishment between processes running on different stations.

Transport layer - The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

CISA review manual 2014 Page number 260

QUESTION 423

Which of the following layer of an OSI model controls dialog between computers?

- A. Application layer
- B. Presentation layer
- C. Session layer
- D. Transport layer

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The session layer allows session establishment between processes running on different stations. It provides:

Session establishment, maintenance and termination: allows two application processes on different machines to establish, use and terminate a connection, called a session. Session support: performs the functions that allow these processes to communicate over the network, performing security, name recognition, logging, and so on.

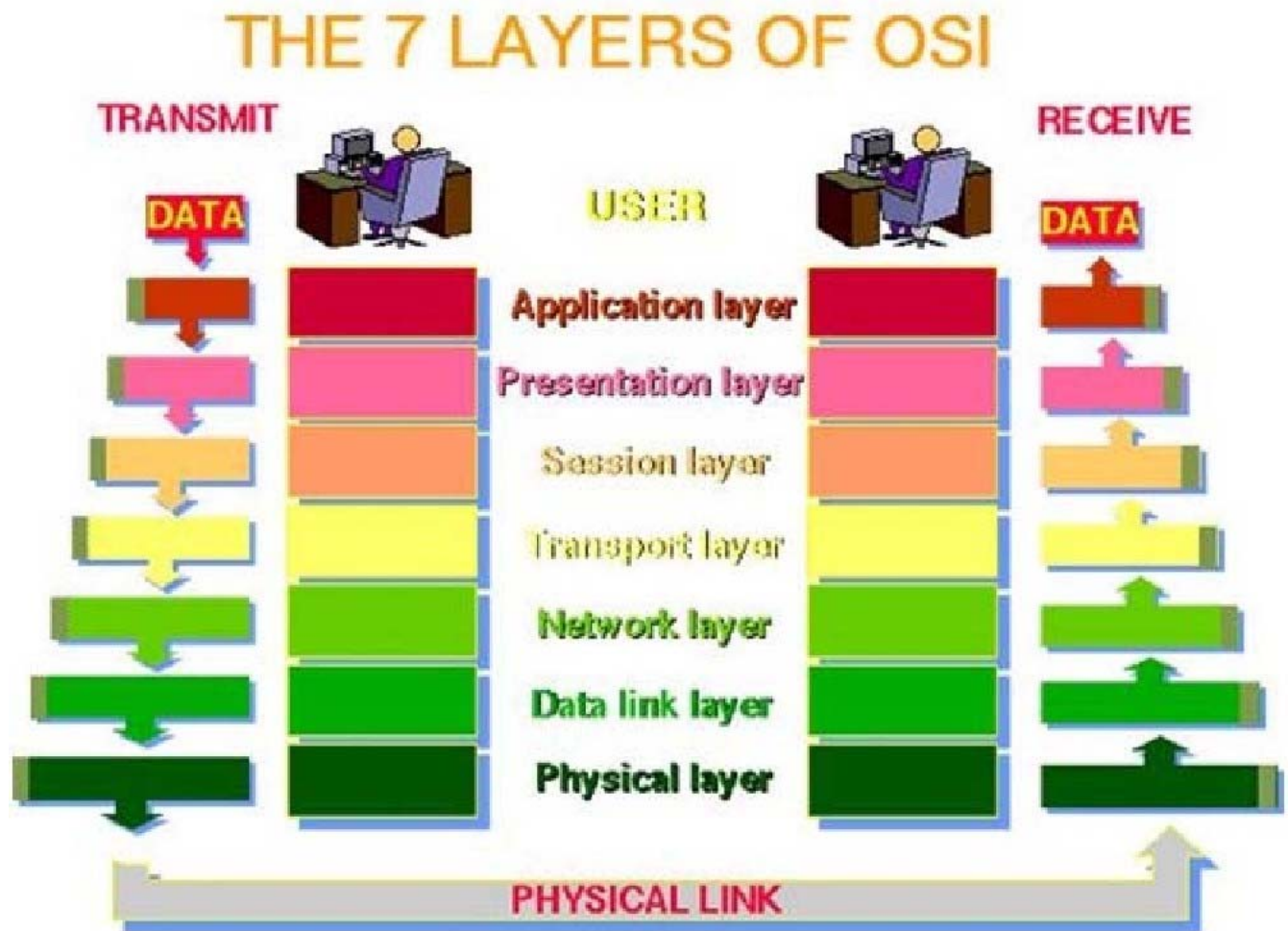
For your exam you should know below information about OSI model:

The Open Systems Interconnection model (OSI) is a conceptual model that characterizes and standardizes the internal functions of a communication system by partitioning it into abstraction layers. The model is a product of the Open Systems Interconnection project at the International Organization for Standardization

(ISO), maintained by the identification ISO/IEC 7498-1.

The model groups communication functions into seven logical layers. A layer serves the layer above it and is served by the layer below it. For example, a layer that provides error-free communications across a network provides the path needed by applications above it, while it calls the next lower layer to send and receive packets that make up the contents of that path. Two instances at one layer are connected by a horizontal.

OSI Model



PHYSICAL LAYER

The physical layer, the lowest layer of the OSI model, is concerned with the transmission and reception of the unstructured raw bit stream over a physical medium. It describes the electrical/optical, mechanical, and functional interfaces to the physical medium, and carries the signals for all of the higher layers. It provides:

Data encoding: modifies the simple digital signal pattern (1s and 0s) used by the PC to better accommodate

the characteristics of the physical medium, and to aid in bit and frame synchronization. It determines:

What signal state represents a binary 1

How the receiving station knows when a "bit-time" starts

How the receiving station delimits a frame

DATA LINK LAYER

The data link layer provides error-free transfer of data frames from one node to another over the physical layer, allowing layers above it to assume virtually error-free transmission over the link. To do this, the data link layer provides:

Link establishment and termination: establishes and terminates the logical link between two nodes. Frame traffic control: tells the transmitting node to "back-off" when no frame buffers are available.

Frame sequencing: transmits/receives frames sequentially.

Frame acknowledgment: provides/expects frame acknowledgments. Detects and recovers from errors that occur in the physical layer by retransmitting non-acknowledged frames and handling duplicate frame receipt.

Frame delimiting: creates and recognizes frame boundaries.

Frame error checking: checks received frames for integrity.

Media access management: determines when the node "has the right" to use the physical medium.

NETWORK LAYER

The network layer controls the operation of the subnet, deciding which physical path the data should take based on network conditions, priority of service, and other factors. It provides:

Routing: routes frames among networks.

Subnet traffic control: routers (network layer intermediate systems) can instruct a sending station to "throttle back" its frame transmission when the router's buffer fills up. Frame fragmentation: if it determines that a downstream router's maximum transmission unit (MTU) size is less than the frame size, a router can fragment a frame for transmission and re-assembly at the destination station.

Logical-physical address mapping: translates logical addresses, or names, into physical addresses. Subnet usage accounting: has accounting functions to keep track of frames forwarded by subnet intermediate systems, to produce billing information.

Communications Subnet

The network layer software must build headers so that the network layer software residing in the subnet intermediate systems can recognize them and use them to route data to the destination address.

This layer relieves the upper layers of the need to know anything about the data transmission and intermediate switching technologies used to connect systems. It establishes, maintains and terminates connections across the intervening communications facility (one or several intermediate systems in the communication subnet).

In the network layer and the layers below, peer protocols exist between a node and its immediate neighbor, but the neighbor may be a node through which data is routed, not the destination station. The source and destination stations may be separated by many intermediate systems.

TRANSPORT LAYER

The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

The size and complexity of a transport protocol depends on the type of service it can get from the network layer. For a reliable network layer with virtual circuit capability, a minimal transport layer is required. If the network layer is unreliable and/or only supports datagram's, the transport protocol should include extensive error detection and recovery.

The transport layer provides:

Message segmentation: accepts a message from the (session) layer above it, splits the message into smaller units (if not already small enough), and passes the smaller units down to the network layer. The transport layer at the destination station reassembles the message.

Message acknowledgment: provides reliable end-to-end message delivery with acknowledgments.

Message traffic control: tells the transmitting station to "back-off" when no message buffers are available. Session multiplexing: multiplexes several message streams, or sessions onto one logical link and keeps track of which messages belong to which sessions (see session layer).

Typically, the transport layer can accept relatively large messages, but there are strict message size limits imposed by the network (or lower) layer. Consequently, the transport layer must break up the messages into smaller units, or frames, pretending a header to each frame.

The transport layer header information must then include control information, such as message start and message end flags, to enable the transport layer on the other end to recognize message boundaries. In addition, if the lower layers do not maintain sequence, the transport header must contain sequence information to enable the transport layer on the receiving end to get the pieces back together in the right order before handing the received message up to the layer above.

End-to-end layers

Unlike the lower "subnet" layers whose protocol is between immediately adjacent nodes, the transport layer and the layers above are true "source to destination" or end-to-end layers, and are not concerned with the details of the underlying communications facility. Transport layer software (and software above it) on the source station carries on a conversation with similar software on the destination station by using message headers and control messages.

SESSION LAYER

The session layer allows session establishment between processes running on different stations. It provides:

Session establishment, maintenance and termination: allows two application processes on different machines to establish, use and terminate a connection, called a session. Session support: performs the functions that allow these processes to communicate over the network, performing security, name recognition, logging, and so on.

PRESENTATION LAYER

The presentation layer formats the data to be presented to the application layer. It can be viewed as the translator for the network. This layer may translate data from a format used by the application layer into a common format at the sending station, then translate the common format to a format known to the application layer at the receiving station.

The presentation layer provides:

Character code translation: for example, ASCII to EBCDIC.

Data conversion: bit order, CR-CR/LF, integer-floating point, and so on. Data compression: reduces the number of bits that need to be transmitted on the network.

Data encryption: encrypt data for security purposes. For example, password encryption.

APPLICATION LAYER

The application layer serves as the window for users and application processes to access network services.

This layer contains a variety of commonly needed functions:

Resource sharing and device redirection

Remote file access

Remote printer access

Inter-process communication

Network management

Directory services

Electronic messaging (such as mail)

Network virtual terminals

The following were incorrect answers:

Application Layer - The application layer serves as the window for users and application processes to access network services.

Presentation layer - The presentation layer formats the data to be presented to the application layer. It can be viewed as the translator for the network. This layer may translate data from a format used by the application layer into a common format at the sending station, then translate the common format to a format known to the

application layer at the receiving station.

Transport layer - The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

CISA review manual 2014 Page number 260

QUESTION 424

Which of the following layer of an OSI model ensures that messages are delivered error-free, in sequence, and with no losses or duplications?

- A. Application layer
- B. Presentation layer
- C. Session layer
- D. Transport layer

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

The size and complexity of a transport protocol depends on the type of service it can get from the network layer. For a reliable network layer with virtual circuit capability, a minimal transport layer is required. If the network layer is unreliable and/or only supports datagram's, the transport protocol should include extensive

error detection and recovery.

The transport layer provides:

Message segmentation: accepts a message from the (session) layer above it, splits the message into smaller units (if not already small enough), and passes the smaller units down to the network layer. The transport layer at the destination station reassembles the message.

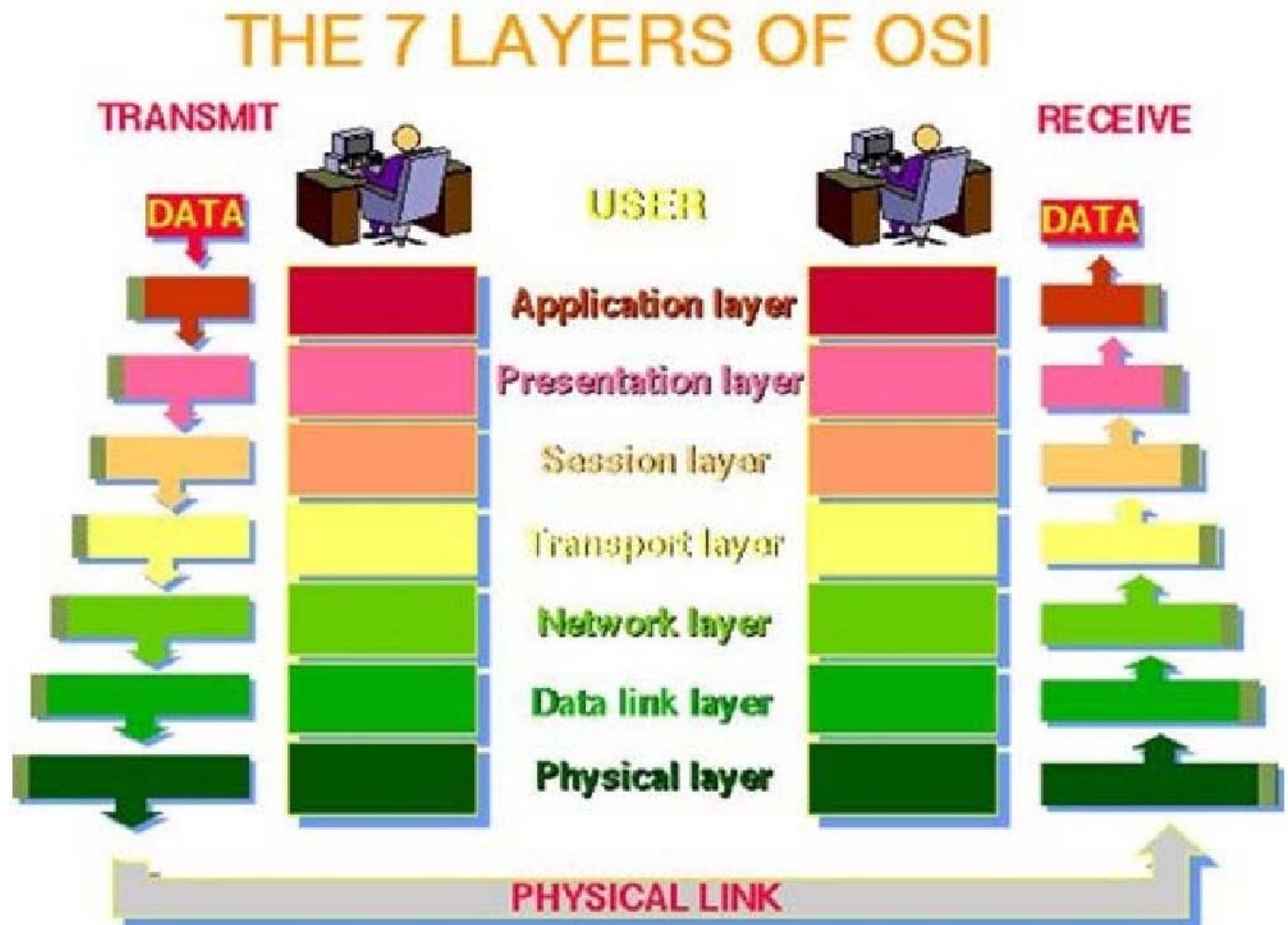
Message acknowledgment: provides reliable end-to-end message delivery with acknowledgments. Message traffic control: tells the transmitting station to "back-off" when no message buffers are available. Session multiplexing: multiplexes several message streams, or sessions onto one logical link and keeps track of which messages belong to which sessions (see session layer).

For your exam you should know below information about OSI model:

The Open Systems Interconnection model (OSI) is a conceptual model that characterizes and standardizes the internal functions of a communication system by partitioning it into abstraction layers. The model is a product of the Open Systems Interconnection project at the International Organization for Standardization (ISO), maintained by the identification ISO/IEC 7498-1.

The model groups communication functions into seven logical layers. A layer serves the layer above it and is served by the layer below it. For example, a layer that provides error-free communications across a network provides the path needed by applications above it, while it calls the next lower layer to send and receive packets that make up the contents of that path. Two instances at one layer are connected by a horizontal.

OSI Model



PHYSICAL LAYER

The physical layer, the lowest layer of the OSI model, is concerned with the transmission and reception of the unstructured raw bit stream over a physical medium. It describes the electrical/optical, mechanical, and functional interfaces to the physical medium, and carries the signals for all of the higher layers. It provides:

Data encoding: modifies the simple digital signal pattern (1s and 0s) used by the PC to better accommodate the characteristics of the physical medium, and to aid in bit and frame synchronization. It determines:

What signal state represents a binary 1

How the receiving station knows when a "bit-time" starts

How the receiving station delimits a frame

DATA LINK LAYER

The data link layer provides error-free transfer of data frames from one node to another over the physical layer, allowing layers above it to assume virtually error-free transmission over the link. To do this, the data link layer provides:

Link establishment and termination: establishes and terminates the logical link between two nodes. Frame traffic control: tells the transmitting node to "back-off" when no frame buffers are available.

Frame sequencing: transmits/receives frames sequentially.

Frame acknowledgment: provides/expects frame acknowledgments. Detects and recovers from errors that occur in the physical layer by retransmitting non-acknowledged frames and handling duplicate frame receipt.

Frame delimiting: creates and recognizes frame boundaries.

Frame error checking: checks received frames for integrity.

Media access management: determines when the node "has the right" to use the physical medium.

NETWORK LAYER

The network layer controls the operation of the subnet, deciding which physical path the data should take based on network conditions, priority of service, and other factors. It provides:

Routing: routes frames among networks.

Subnet traffic control: routers (network layer intermediate systems) can instruct a sending station to "throttle back" its frame transmission when the router's buffer fills up. Frame fragmentation: if it determines that a downstream router's maximum transmission unit (MTU) size is less than the frame size, a router can fragment a frame for transmission and re-assembly at the destination station.

Logical-physical address mapping: translates logical addresses, or names, into physical addresses. Subnet usage accounting: has accounting functions to keep track of frames forwarded by subnet intermediate systems, to produce billing information.

Communications Subnet

The network layer software must build headers so that the network layer software residing in the subnet intermediate systems can recognize them and use them to route data to the destination address.

This layer relieves the upper layers of the need to know anything about the data transmission and intermediate switching technologies used to connect systems. It establishes, maintains and terminates connections across the intervening communications facility (one or several intermediate systems in the communication subnet).

In the network layer and the layers below, peer protocols exist between a node and its immediate neighbor, but the neighbor may be a node through which data is routed, not the destination station. The source and destination stations may be separated by many intermediate systems.

TRANSPORT LAYER

The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

The size and complexity of a transport protocol depends on the type of service it can get from the network layer. For a reliable network layer with virtual circuit capability, a minimal transport layer is required. If the network layer is unreliable and/or only supports datagram's, the transport protocol should include extensive error detection and recovery.

The transport layer provides:

Message segmentation: accepts a message from the (session) layer above it, splits the message into smaller units (if not already small enough), and passes the smaller units down to the network layer. The transport layer at the destination station reassembles the message.

Message acknowledgment: provides reliable end-to-end message delivery with acknowledgments. Message traffic control: tells the transmitting station to "back-off" when no message buffers are available. Session multiplexing: multiplexes several message streams, or sessions onto one logical link and keeps track of which messages belong to which sessions (see session layer).

Typically, the transport layer can accept relatively large messages, but there are strict message size limits imposed by the network (or lower) layer. Consequently, the transport layer must break up the messages into smaller units, or frames, pretending a header to each frame.

The transport layer header information must then include control information, such as message start and message end flags, to enable the transport layer on the other end to recognize message boundaries. In addition, if the lower layers do not maintain sequence, the transport header must contain sequence information to enable the transport layer on the receiving end to get the pieces back together in the right order before handing the received message up to the layer above.

End-to-end layers

Unlike the lower "subnet" layers whose protocol is between immediately adjacent nodes, the transport layer and the layers above are true "source to destination" or end-to-end layers, and are not concerned with the details of the underlying communications facility. Transport layer software (and software above it) on the source station carries on a conversation with similar software on the destination station by using message headers and control messages.

SESSION LAYER

The session layer allows session establishment between processes running on different stations. It provides:

Session establishment, maintenance and termination: allows two application processes on different machines to establish, use and terminate a connection, called a session. Session support: performs the functions that allow these processes to communicate over the network, performing security, name recognition, logging, and so on.

PRESENTATION LAYER

The presentation layer formats the data to be presented to the application layer. It can be viewed as the translator for the network. This layer may translate data from a format used by the application layer into a common format at the sending station, then translate the common format to a format known to the application layer at the receiving station.

The presentation layer provides:

Character code translation: for example, ASCII to EBCDIC.

Data conversion: bit order, CR-CR/LF, integer-floating point, and so on. Data compression: reduces the number of bits that need to be transmitted on the network.

Data encryption: encrypt data for security purposes. For example, password encryption.

APPLICATION LAYER

The application layer serves as the window for users and application processes to access network services.

This layer contains a variety of commonly needed functions:

Resource sharing and device redirection

Remote file access

Remote printer access

Inter-process communication

Network management

Directory services

Electronic messaging (such as mail)

Network virtual terminals

The following were incorrect answers:

Application Layer - The application layer serves as the window for users and application processes to access network services.

Presentation layer - The presentation layer formats the data to be presented to the application layer. It can be viewed as the translator for the network. This layer may translate data from a format used by the application

layer into a common format at the sending station, then translate the common format to a format known to the application layer at the receiving station.

Session layer - The session layer allows session establishment between processes running on different stations.

CISA review manual 2014 Page number 260

QUESTION 425

Which of the following layer of an OSI model responsible for routing and forwarding of a network packets?

- A. Transport Layer
- B. Network Layer
- C. Data Link Layer
- D. Physical Layer

Correct Answer: B
Explanation

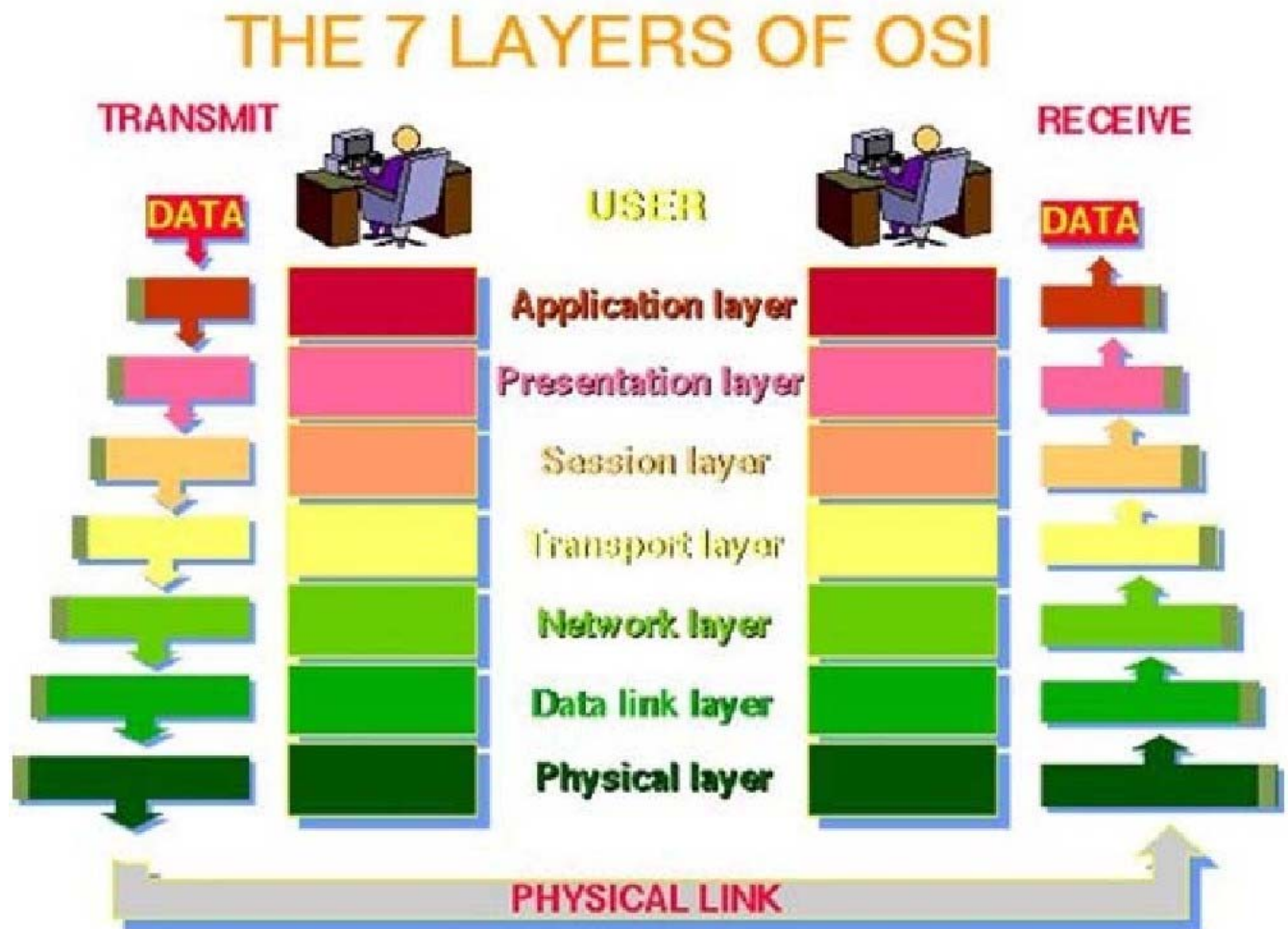
Explanation/Reference:

Section: Information System Operations, Maintenance and Support The network layer controls the operation of the subnet, deciding which physical path the data should take based on network conditions, priority of service, and other factors.

For CISA exam you should know below information about OSI model:

The Open Systems Interconnection model (OSI) is a conceptual model that characterizes and standardizes the internal functions of a communication system by partitioning it into abstraction layers. The model is a product of the Open Systems Interconnection project at the International Organization for Standardization (ISO), maintained by the identification ISO/IEC 7498-1.

The model groups communication functions into seven logical layers. A layer serves the layer above it and is served by the layer below it. For example, a layer that provides error-free communications across a network provides the path needed by applications above it, while it calls the next lower layer to send and receive packets that make up the contents of that path. Two instances at one layer are connected by a horizontal.OSI Model



PHYSICAL LAYER

The physical layer, the lowest layer of the OSI model, is concerned with the transmission and reception of the unstructured raw bit stream over a physical medium. It describes the electrical/optical, mechanical, and functional interfaces to the physical medium, and carries the signals for all of the higher layers. It provides:

Data encoding: modifies the simple digital signal pattern (1s and 0s) used by the PC to better accommodate the characteristics of the physical medium, and to aid in bit and frame synchronization. It determines:

- What signal state represents a binary 1
- How the receiving station knows when a "bit-time" starts
- How the receiving station delimits a frame

DATA LINK LAYER

The data link layer provides error-free transfer of data frames from one node to another over the physical layer, allowing layers above it to assume virtually error-free transmission over the link. To do this, the data link layer provides:

- Link establishment and termination: establishes and terminates the logical link between two nodes.
- Frame traffic control: tells the transmitting node to "back-off" when no frame buffers are available.
- Frame sequencing: transmits/receives frames sequentially.
- Frame acknowledgment: provides/expects frame acknowledgments. Detects and recovers from errors that occur in the physical layer by retransmitting non-acknowledged frames and handling duplicate frame receipt.
- Frame delimiting: creates and recognizes frame boundaries.
- Frame error checking: checks received frames for integrity.
- Media access management: determines when the node "has the right" to use the physical medium.

NETWORK LAYER

The network layer controls the operation of the subnet, deciding which physical path the data should take based on network conditions, priority of service, and

other factors. It provides:

Routing: routes frames among networks.

Subnet traffic control: routers (network layer intermediate systems) can instruct a sending station to "throttle back" its frame transmission when the router's buffer fills up. Frame fragmentation: if it determines that a downstream router's maximum transmission unit (MTU) size is less than the frame size, a router can fragment a frame for transmission and re-assembly at the destination station.

Logical-physical address mapping: translates logical addresses, or names, into physical addresses. Subnet usage accounting: has accounting functions to keep track of frames forwarded by subnet intermediate systems, to produce billing information.

Communications Subnet

The network layer software must build headers so that the network layer software residing in the subnet intermediate systems can recognize them and use them to route data to the destination address.

This layer relieves the upper layers of the need to know anything about the data transmission and intermediate switching technologies used to connect systems. It establishes, maintains and terminates connections across the intervening communications facility (one or several intermediate systems in the communication subnet).

In the network layer and the layers below, peer protocols exist between a node and its immediate neighbor, but the neighbor may be a node through which data is routed, not the destination station. The source and destination stations may be separated by many intermediate systems.

TRANSPORT LAYER

The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

The size and complexity of a transport protocol depends on the type of service it can get from the network layer. For a reliable network layer with virtual circuit capability, a minimal transport layer is required. If the network layer is unreliable and/or only supports datagram's, the transport protocol should include extensive error detection and recovery.

The transport layer provides:

Message segmentation: accepts a message from the (session) layer above it, splits the message into smaller units (if not already small enough), and passes the smaller units down to the network layer. The transport layer at the destination station reassembles the message.

Message acknowledgment: provides reliable end-to-end message delivery with acknowledgments. Message traffic control: tells the transmitting station to "back-off" when no message buffers are available. Session multiplexing: multiplexes several message streams, or sessions onto one logical link and keeps track of which messages belong to which sessions (see session layer). Typically, the transport layer can accept relatively large messages, but there are strict message size limits imposed by the network (or lower) layer. Consequently, the transport layer must break up the messages into smaller units, or frames, pretending a header to each frame.

The transport layer header information must then include control information, such as message start and message end flags, to enable the transport layer on the other end to recognize message boundaries. In addition, if the lower layers do not maintain sequence, the transport header must contain sequence information to enable the transport layer on the receiving end to get the pieces back together in the right order before handing the received message up to the layer above.

End-to-end layers

Unlike the lower "subnet" layers whose protocol is between immediately adjacent nodes, the transport layer and the layers above are true "source to destination" or end-to-end layers, and are not concerned with the details of the underlying communications facility. Transport layer software (and software above it) on the source station carries on a conversation with similar software on the destination station by using message headers and control messages.

SESSION LAYER

The session layer allows session establishment between processes running on different stations. It provides:

Session establishment, maintenance and termination: allows two application processes on different machines to establish, use and terminate a connection, called a session. Session support: performs the functions that allow these processes to communicate over the network, performing security, name recognition, logging, and so on.

PRESENTATION LAYER

The presentation layer formats the data to be presented to the application layer. It can be viewed as the translator for the network. This layer may translate data from a format used by the application layer into a common format at the sending station, then translate the common format to a format known to the application layer at the receiving station.

The presentation layer provides:

Character code translation: for example, ASCII to EBCDIC.

Data conversion: bit order, CR-CR/LF, integer-floating point, and so on. Data compression: reduces the number of bits that need to be transmitted on the network.

Data encryption: encrypt data for security purposes. For example, password encryption.

APPLICATION LAYER

The application layer serves as the window for users and application processes to access network services.

This layer contains a variety of commonly needed functions:

Resource sharing and device redirection

Remote file access

Remote printer access

Inter-process communication

Network management

Directory services

Electronic messaging (such as mail)

Network virtual terminals

The following were incorrect answers:

Transport layer - The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

Data link layer - The data link layer provides error-free transfer of data frames from one node to another over the physical layer, allowing layers above it to assume virtually error-free transmission over the link. Physical Layer - The physical layer, the lowest layer of the OSI model, is concerned with the transmission and reception of the unstructured raw bit stream over a physical medium. It describes the electrical/optical, mechanical, and functional interfaces to the physical medium, and carries the signals for all of the higher layers.

CISA review manual 2014 Page number 260

QUESTION 426

Which of the following layer of an OSI model encapsulates packets into frames?

- A. Transport Layer
- B. Network Layer
- C. Data Link Layer
- D. Physical Layer

Correct Answer: C

Explanation

Explanation/Reference:

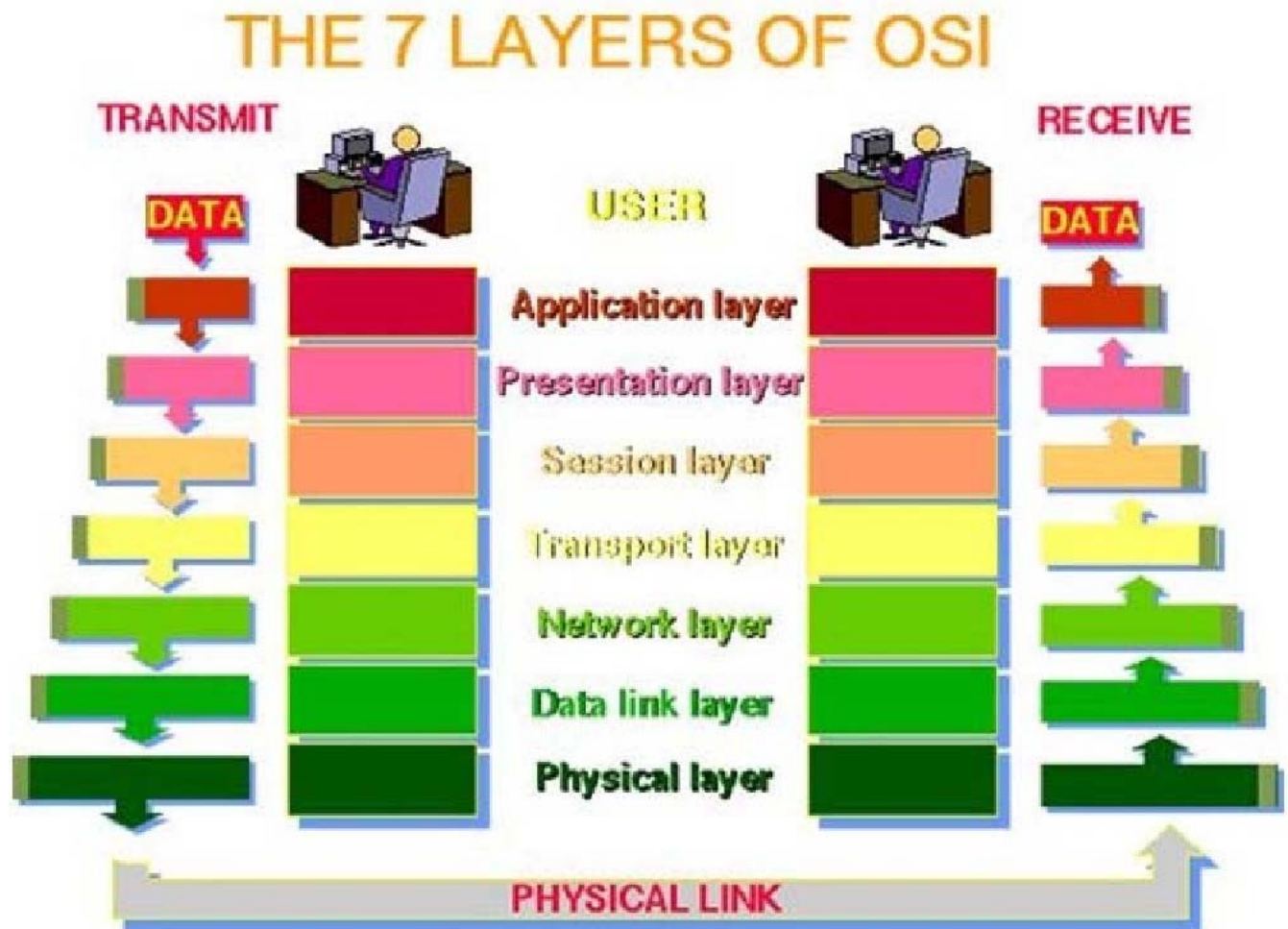
Section: Information System Operations, Maintenance and Support The data link layer provides error-free transfer of data frames from one node to another over the physical layer, allowing layers above it to assume virtually error-free transmission over the link.

For your exam you should know below information about OSI model:

The Open Systems Interconnection model (OSI) is a conceptual model that characterizes and standardizes the internal functions of a communication system by partitioning it into abstraction layers. The model is a product of the Open Systems Interconnection project at the International Organization for Standardization (ISO), maintained by the identification ISO/IEC 7498-1.

The model groups communication functions into seven logical layers. A layer serves the layer above it and is served by the layer below it. For example, a layer that provides error-free communications across a network provides the path needed by applications above it, while it calls the next lower layer to send and receive packets that make up the contents of that path. Two instances at one layer are connected by a horizontal.

OSI Model

**PHYSICAL LAYER**

The physical layer, the lowest layer of the OSI model, is concerned with the transmission and reception of the unstructured raw bit stream over a physical medium. It describes the electrical/optical, mechanical, and functional interfaces to the physical medium, and carries the signals for all of the higher layers. It provides:

Data encoding: modifies the simple digital signal pattern (1s and 0s) used by the PC to better accommodate the characteristics of the physical medium, and to aid in bit and frame synchronization. It determines:

What signal state represents a binary 1

How the receiving station knows when a "bit-time" starts

How the receiving station delimits a frame

DATA LINK LAYER

The data link layer provides error-free transfer of data frames from one node to another over the physical layer, allowing layers above it to assume virtually error-free transmission over the link. To do this, the data link layer provides:

Link establishment and termination: establishes and terminates the logical link between two nodes. Frame traffic control: tells the transmitting node to "back-off" when no frame buffers are available.

Frame sequencing: transmits/receives frames sequentially.

Frame acknowledgment: provides/expects frame acknowledgments. Detects and recovers from errors that occur in the physical layer by retransmitting non-acknowledged frames and handling duplicate frame receipt.

Frame delimiting: creates and recognizes frame boundaries.

Frame error checking: checks received frames for integrity.

Media access management: determines when the node "has the right" to use the physical medium.

NETWORK LAYER

The network layer controls the operation of the subnet, deciding which physical path the data should take based on network conditions, priority of service, and other factors. It provides:

Routing: routes frames among networks.

Subnet traffic control: routers (network layer intermediate systems) can instruct a sending station to "throttle back" its frame transmission when the router's buffer

fills up. Frame fragmentation: if it determines that a downstream router's maximum transmission unit (MTU) size is less than the frame size, a router can fragment a frame for transmission and re-assembly at the destination station.

Logical-physical address mapping: translates logical addresses, or names, into physical addresses. Subnet usage accounting: has accounting functions to keep track of frames forwarded by subnet intermediate systems, to produce billing information.

Communications Subnet

The network layer software must build headers so that the network layer software residing in the subnet intermediate systems can recognize them and use them to route data to the destination address.

This layer relieves the upper layers of the need to know anything about the data transmission and intermediate switching technologies used to connect systems. It establishes, maintains and terminates connections across the intervening communications facility (one or several intermediate systems in the communication subnet).

In the network layer and the layers below, peer protocols exist between a node and its immediate neighbor, but the neighbor may be a node through which data is routed, not the destination station. The source and destination stations may be separated by many intermediate systems.

TRANSPORT LAYER

The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

The size and complexity of a transport protocol depends on the type of service it can get from the network layer. For a reliable network layer with virtual circuit capability, a minimal transport layer is required. If the network layer is unreliable and/or only supports datagram's, the transport protocol should include extensive error detection and recovery.

The transport layer provides:

Message segmentation: accepts a message from the (session) layer above it, splits the message into smaller units (if not already small enough), and passes the smaller units down to the network layer. The transport layer at the destination station reassembles the message.

Message acknowledgment: provides reliable end-to-end message delivery with acknowledgments. Message traffic control: tells the transmitting station to "back-off" when no message buffers are available. Session multiplexing: multiplexes several message streams, or sessions onto one logical link and keeps track of which messages belong to which sessions (see session layer).

Typically, the transport layer can accept relatively large messages, but there are strict message size limits imposed by the network (or lower) layer. Consequently, the transport layer must break up the messages into smaller units, or frames, pretending a header to each frame.

The transport layer header information must then include control information, such as message start and message end flags, to enable the transport layer on the other end to recognize message boundaries. In addition, if the lower layers do not maintain sequence, the transport header must contain sequence information to enable the transport layer on the receiving end to get the pieces back together in the right order before handing the received message up to the layer above.

End-to-end layers

Unlike the lower "subnet" layers whose protocol is between immediately adjacent nodes, the transport layer and the layers above are true "source to destination" or end-to-end layers, and are not concerned with the details of the underlying communications facility. Transport layer software (and software above it) on the source station carries on a conversation with similar software on the destination station by using message headers and control messages.

SESSION LAYER

The session layer allows session establishment between processes running on different stations. It provides:

Session establishment, maintenance and termination: allows two application processes on different machines to establish, use and terminate a connection, called a session. Session support: performs the functions that allow these processes to communicate over the network, performing security, name recognition, logging, and so on.

PRESENTATION LAYER

The presentation layer formats the data to be presented to the application layer. It can be viewed as the translator for the network. This layer may translate data from a format used by the application layer into a common format at the sending station, then translate the common format to a format known to the application layer at the receiving station.

The presentation layer provides:

Character code translation: for example, ASCII to EBCDIC.

Data conversion: bit order, CR-CR/LF, integer-floating point, and so on. Data compression: reduces the number of bits that need to be transmitted on the network.

Data encryption: encrypt data for security purposes. For example, password encryption.

APPLICATION LAYER

The application layer serves as the window for users and application processes to access network services.

This layer contains a variety of commonly needed functions:

Resource sharing and device redirection

Remote file access

Remote printer access

Inter-process communication

Network management

Directory services

Electronic messaging (such as mail)

Network virtual terminals

The following were incorrect answers:

Transport layer - The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

Network layer - The network layer controls the operation of the subnet, deciding which physical path the data

should take based on network conditions, priority of service, and other factors. Physical Layer - The physical layer, the lowest layer of the OSI model, is concerned with the transmission and reception of the unstructured raw bit stream over a physical medium. It describes the electrical/optical, mechanical, and functional interfaces to the physical medium, and carries the signals for all of the higher layers.

CISA review manual 2014 Page number 260

QUESTION 427

Which of the following layer of an OSI model transmits and receives the bit stream as electrical, optical or radio signals over an appropriate medium or carrier?

- A. Transport Layer
- B. Network Layer
- C. Data Link Layer
- D. Physical Layer

Correct Answer: D

Explanation

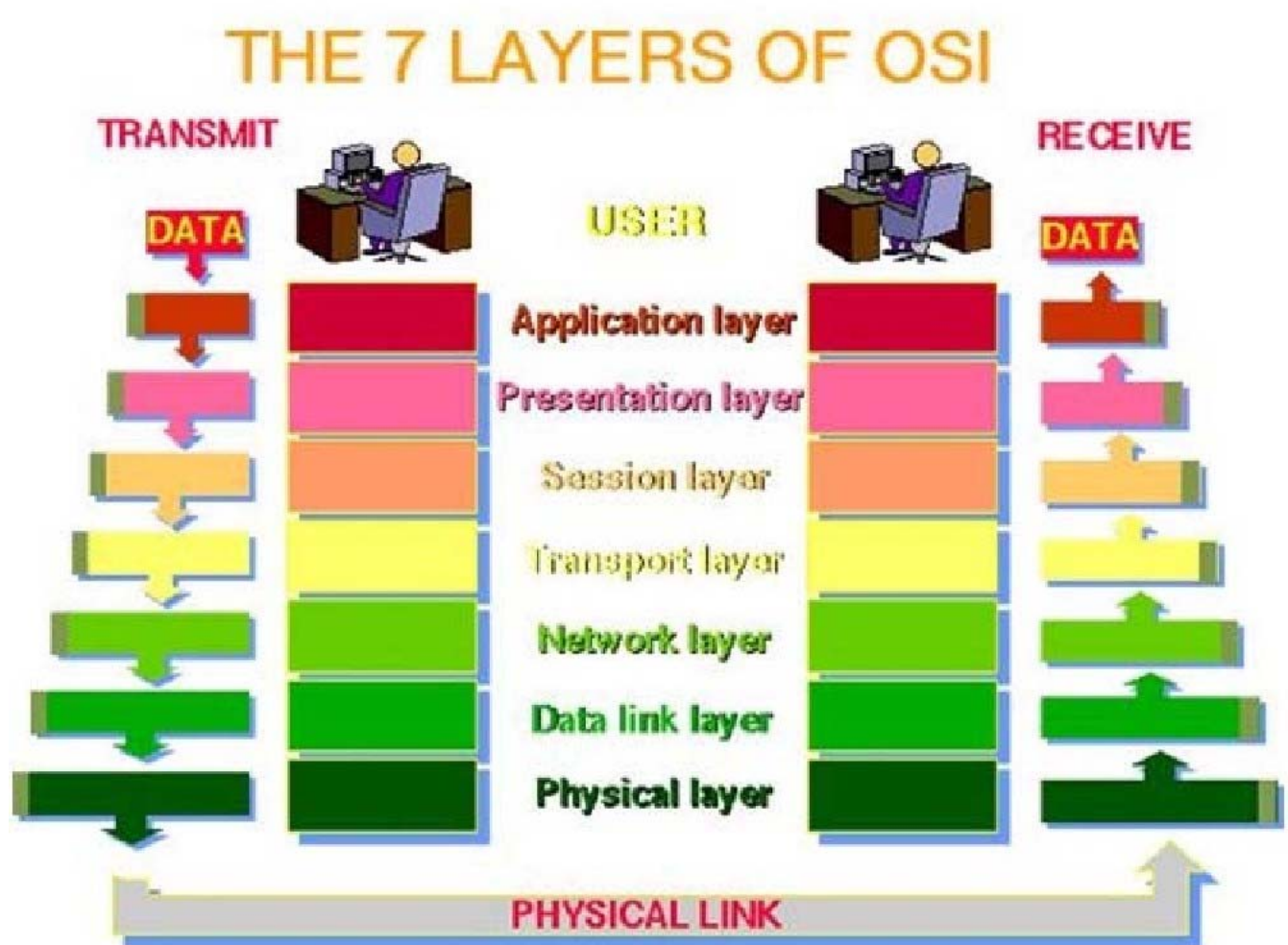
Explanation/Reference:

Section: Information System Operations, Maintenance and Support The physical layer, the lowest layer of the OSI model, is concerned with the transmission and reception of the unstructured raw bit stream over a physical medium. It describes the electrical/optical, mechanical, and functional interfaces to the physical medium, and carries the signals for all of the higher layers.

For your exam you should know below information about OSI model:

The Open Systems Interconnection model (OSI) is a conceptual model that characterizes and standardizes the internal functions of a communication system by partitioning it into abstraction layers. The model is a product of the Open Systems Interconnection project at the International Organization for Standardization (ISO), maintained by the identification ISO/IEC 7498-1.

The model groups communication functions into seven logical layers. A layer serves the layer above it and is served by the layer below it. For example, a layer that provides error-free communications across a network provides the path needed by applications above it, while it calls the next lower layer to send and receive packets that make up the contents of that path. Two instances at one layer are connected by a horizontal. OSI Model



PHYSICAL LAYER

The physical layer, the lowest layer of the OSI model, is concerned with the transmission and reception of the unstructured raw bit stream over a physical medium. It describes the electrical/optical, mechanical, and functional interfaces to the physical medium, and carries the signals for all of the higher layers. It provides:

Data encoding: modifies the simple digital signal pattern (1s and 0s) used by the PC to better accommodate the characteristics of the physical medium, and to aid in bit and frame synchronization. It determines:

What signal state represents a binary 1

How the receiving station knows when a "bit-time" starts

How the receiving station delimits a frame

DATA LINK LAYER

The data link layer provides error-free transfer of data frames from one node to another over the physical layer, allowing layers above it to assume virtually error-free transmission over the link. To do this, the data link layer provides:

Link establishment and termination: establishes and terminates the logical link between two nodes. Frame traffic control: tells the transmitting node to "back-off" when no frame buffers are available.

Frame sequencing: transmits/receives frames sequentially.

Frame acknowledgment: provides/expects frame acknowledgments. Detects and recovers from errors that occur in the physical layer by retransmitting non-acknowledged frames and handling duplicate frame receipt.

Frame delimiting: creates and recognizes frame boundaries.

Frame error checking: checks received frames for integrity.

Media access management: determines when the node "has the right" to use the physical medium.

NETWORK LAYER

The network layer controls the operation of the subnet, deciding which physical path the data should take based on network conditions, priority of service, and other factors. It provides:

Routing: routes frames among networks.

Subnet traffic control: routers (network layer intermediate systems) can instruct a sending station to "throttle back" its frame transmission when the router's buffer

fills up. Frame fragmentation: if it determines that a downstream router's maximum transmission unit (MTU) size is less than the frame size, a router can fragment a frame for transmission and re-assembly at the destination station.

Logical-physical address mapping: translates logical addresses, or names, into physical addresses. Subnet usage accounting: has accounting functions to keep track of frames forwarded by subnet intermediate systems, to produce billing information.

Communications Subnet

The network layer software must build headers so that the network layer software residing in the subnet intermediate systems can recognize them and use them to route data to the destination address.

This layer relieves the upper layers of the need to know anything about the data transmission and intermediate

switching technologies used to connect systems. It establishes, maintains and terminates connections across the intervening communications facility (one or several intermediate systems in the communication subnet).

In the network layer and the layers below, peer protocols exist between a node and its immediate neighbor, but the neighbor may be a node through which data is routed, not the destination station. The source and destination stations may be separated by many intermediate systems.

TRANSPORT LAYER

The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

The size and complexity of a transport protocol depends on the type of service it can get from the network layer. For a reliable network layer with virtual circuit capability, a minimal transport layer is required. If the network layer is unreliable and/or only supports datagram's, the transport protocol should include extensive error detection and recovery.

The transport layer provides:

Message segmentation: accepts a message from the (session) layer above it, splits the message into smaller units (if not already small enough), and passes the smaller units down to the network layer. The transport layer at the destination station reassembles the message.

Message acknowledgment: provides reliable end-to-end message delivery with acknowledgments. Message traffic control: tells the transmitting station to "back-off" when no message buffers are available. Session multiplexing: multiplexes several message streams, or sessions onto one logical link and keeps track of which messages belong to which sessions (see session layer).

Typically, the transport layer can accept relatively large messages, but there are strict message size limits imposed by the network (or lower) layer. Consequently, the transport layer must break up the messages into smaller units, or frames, pretending a header to each frame.

The transport layer header information must then include control information, such as message start and message end flags, to enable the transport layer on the other end to recognize message boundaries. In addition, if the lower layers do not maintain sequence, the transport header must contain sequence information to enable the transport layer on the receiving end to get the pieces back together in the right order before handing the received message up to the layer above.

End-to-end layers

Unlike the lower "subnet" layers whose protocol is between immediately adjacent nodes, the transport layer and the layers above are true "source to destination" or end-to-end layers, and are not concerned with the details of the underlying communications facility. Transport layer software (and software above it) on the source station carries on a conversation with similar software on the destination station by using message headers and control messages.

SESSION LAYER

The session layer allows session establishment between processes running on different stations. It provides:

Session establishment, maintenance and termination: allows two application processes on different machines to establish, use and terminate a connection, called a session. Session support: performs the functions that allow these processes to communicate over the network, performing security, name recognition, logging, and so on.

PRESENTATION LAYER

The presentation layer formats the data to be presented to the application layer. It can be viewed as the translator for the network. This layer may translate data from a format used by the application layer into a common format at the sending station, then translate the common format to a format known to the application layer at the receiving station.

The presentation layer provides:

Character code translation: for example, ASCII to EBCDIC.

Data conversion: bit order, CR-CR/LF, integer-floating point, and so on. Data compression: reduces the number of bits that need to be transmitted on the network.

Data encryption: encrypt data for security purposes. For example, password encryption.

APPLICATION LAYER

The application layer serves as the window for users and application processes to access network services.

This layer contains a variety of commonly needed functions:

Resource sharing and device redirection

Remote file access

Remote printer access

Inter-process communication

Network management

Directory services

Electronic messaging (such as mail)

Network virtual terminals

The following were incorrect answers:

Transport layer - The transport layer ensures that messages are delivered error-free, in sequence, and with no losses or duplications. It relieves the higher layer protocols from any concern with the transfer of data between them and their peers.

Network layer - The network layer controls the operation of the subnet, deciding which physical path the data should take based on network conditions, priority of service, and other factors. Data link layer - The data link layer provides error-free transfer of data frames from one node to another over the physical layer, allowing layers above it to assume virtually error-free transmission over the link.

CISA review manual 2014 Page number 260

QUESTION 428

Which of the following statement INCORRECTLY describes network device such as a Router?

- A. Router creates a new header for each packet
- B. Router builds a routing table based on MAC address
- C. Router does not forward broadcast packet
- D. Router assigns a different network address per port

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The INCORRECTLY keyword is used in the question. You need to find out a statement which is not valid about router. Router builds a routing table based on IP address and not on MAC address.

Difference between Router and Bridge:

Router

Bridge

Creates a new header for each packet

Does not alter header. Only reads the header

Builds routing table based on IP address

Build forwarding table based on MAC address

Assigns a different network address per port

Use the same network address for all ports

Filters traffic based on IP address

Filter traffic based on MAC address

Does not forward broadcast packet

Forward broadcast packet

Does not forward traffic that contain destination address unknown to the router

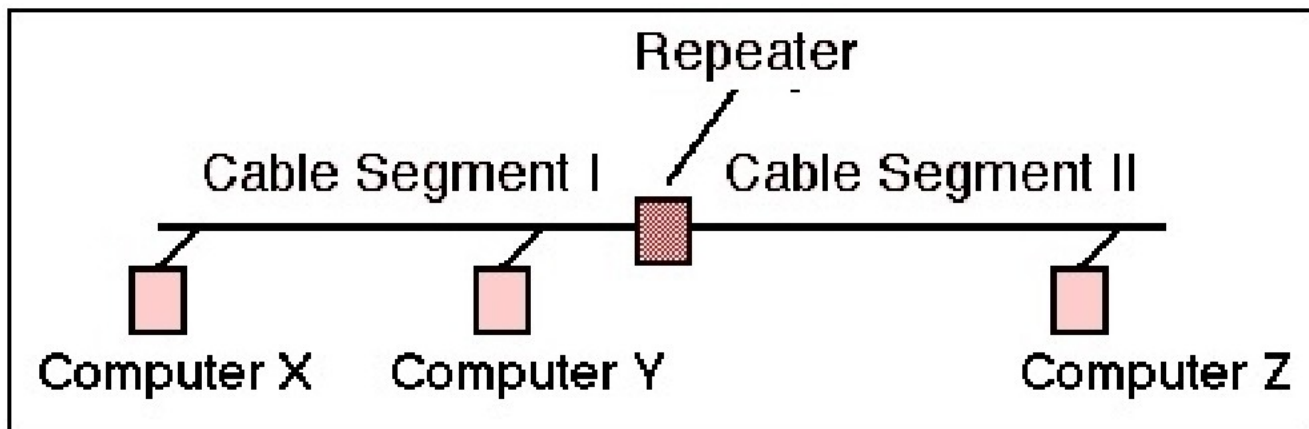
Forward traffic if destination address is unknown to bridge

For your exam you should know below information about network devices:

Repeaters

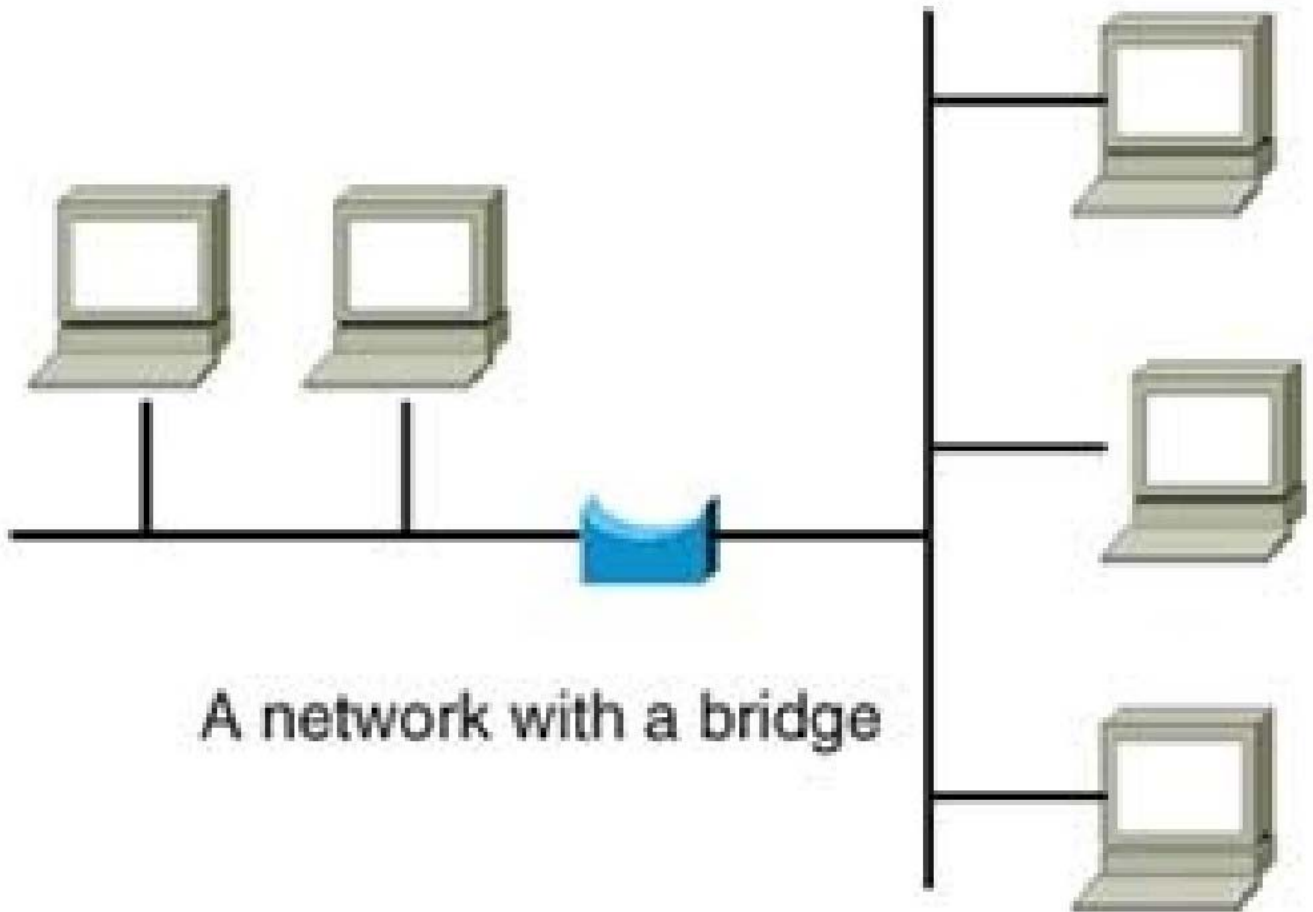
A repeater provides the simplest type of connectivity, because it only repeats electrical signals between cable segments, which enables it to extend a network. Repeaters work at the physical layer and are add-on devices for extending a network connection over a greater distance. The device amplifies signals because signals attenuate the farther they have to travel.

Repeaters can also work as line conditioners by actually cleaning up the signals. This works much better when amplifying digital signals than when amplifying analog signals, because digital signals are discrete units, which makes extraction of background noise from them much easier for the amplifier. If the device is amplifying analog signals, any accompanying noise often is amplified as well, which may further distort the signal. A hub is a multi-port repeater. A hub is often referred to as a concentrator because it is the physical communication device that allows several computers and devices to communicate with each other. A hub does not understand or work with IP or MAC addresses. When one system sends a signal to go to another system connected to it, the signal is broadcast to all the ports, and thus to all the systems connected to the concentrator.

Repeater**Bridges**

A bridge is a LAN device used to connect LAN segments. It works at the data link layer and therefore works with MAC addresses. A repeater does not work with addresses; it just forwards all signals it receives. When a frame arrives at a bridge, the bridge determines whether or not the MAC address is on the local network segment. If the MAC address is not on the local network segment, the bridge forwards the frame to the necessary network segment.

Bridge



Routers

Routers are layer 3, or network layer, devices that are used to connect similar or different networks. (For example, they can connect two Ethernet LANs or an Ethernet LAN to a Token Ring LAN.) A router is a device that has two or more interfaces and a routing table so it knows how to get packets to their destinations. It can filter traffic based on access control lists (ACLs), and it fragments packets when necessary. Because routers have more network-level knowledge, they can perform higher-level functions, such as calculating the shortest and most economical path between the sending and receiving hosts.

Router and Switch

Router



8-port Switch



Switches

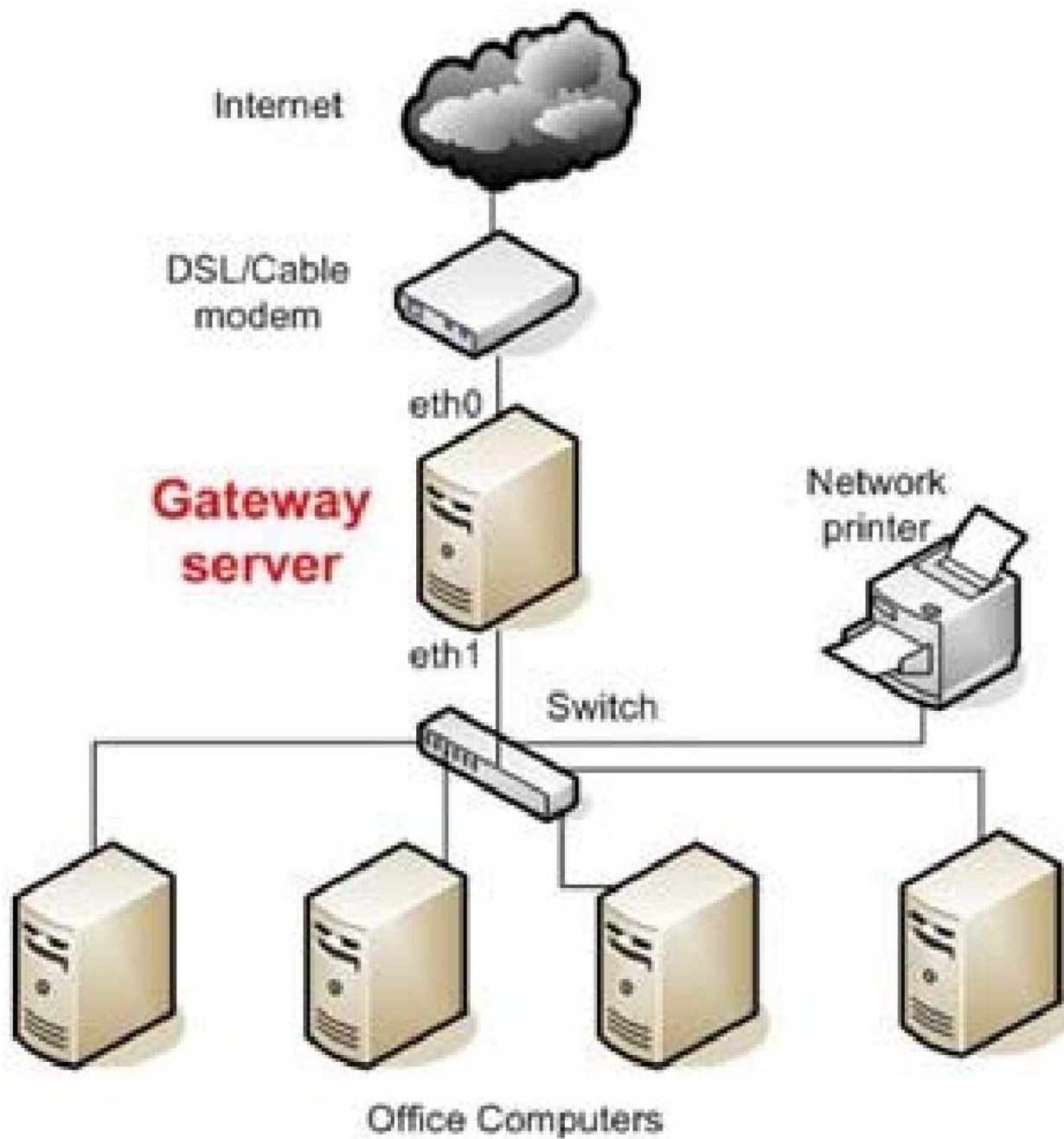
Switches combine the functionality of a repeater and the functionality of a bridge. A switch amplifies the electrical signal, like a repeater, and has the built-in circuitry and intelligence of a bridge. It is a multi-port connection device that provides connections for individual computers or other hubs and switches.

Gateways

Gateway is a general term for software running on a device that connects two different environments and that many times acts as a translator for them or somehow restricts their interactions.

Usually a gateway is needed when one environment speaks a different language, meaning it uses a certain protocol that the other environment does not understand. The gateway can translate Internetwork Packet Exchange (IPX) protocol packets to IP packets, accept mail from one type of mail server and format it so another type of mail server can accept and understand it, or connect and translate different data link technologies such as FDDI to Ethernet.

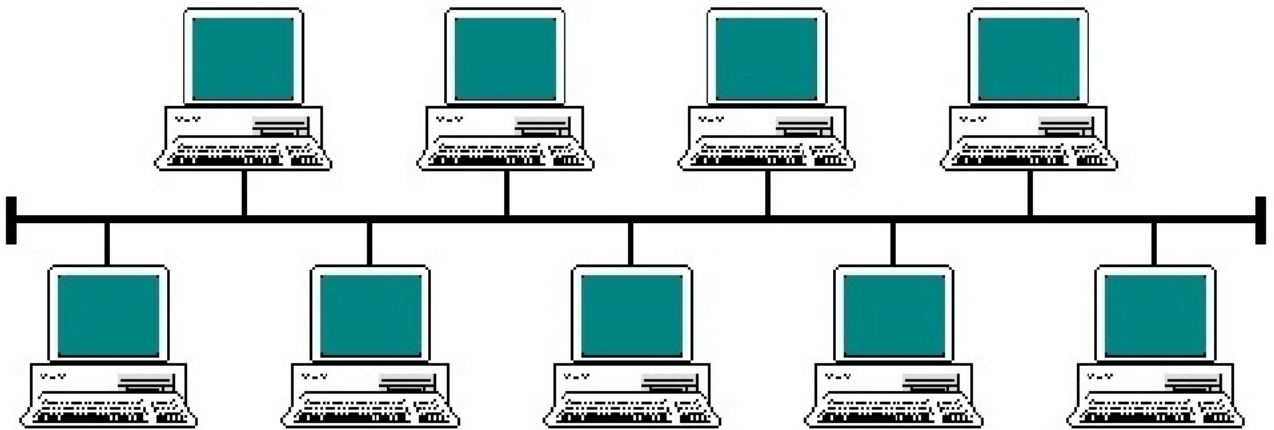
Gateway Server



The following were incorrect answers:
The other options presented correctly describes about Router.
CISA review manual 2014 Page number 263

QUESTION 429

Identify the LAN topology from below diagram presented below:



bus topology

- A. Bus
- B. Star
- C. Ring
- D. Mesh

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support For your exam you should know the information below related to LAN topologies:

LAN Topologies

Network topology is the physical arrangement of the various elements (links, nodes, etc.) of a computer network.

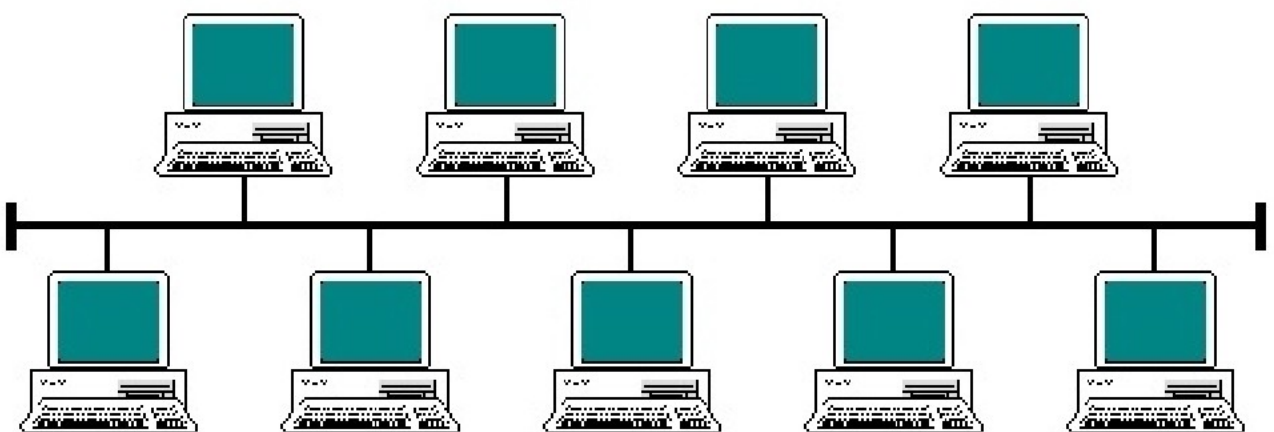
Essentially, it is the topological structure of a network, and may be depicted physically or logically. Physical topology refers to the placement of the network's various components, including device location and cable installation, while logical topology shows how data flows within a network, regardless of its physical design.

Distances between nodes, physical interconnections, transmission rates, and/or signal types may differ between two networks, yet their topologies may be identical.

Bus

In local area networks where bus topology is used, each node is connected to a single cable. Each computer or server is connected to the single bus cable. A signal from the source travels in both directions to all machines connected on the bus cable until it finds the intended recipient. If the machine address does not match the intended address for the data, the machine ignores the data. Alternatively, if the data matches the machine address, the data is accepted. Since the bus topology consists of only one wire, it is rather inexpensive to implement when compared to other topologies. However, the low cost of implementing the technology is offset by the high cost of managing the network. Additionally, since only one cable is utilized, it can be the single point of failure. If the network cable is terminated on both ends and when without termination data transfer stop and when cable breaks, the entire network will be down.

Bus topology



Linear bus

The type of network topology in which all of the nodes of the network are connected to a common transmission medium which has exactly two endpoints (this is the 'bus', which is also commonly referred to as the backbone, or trunk) all data that is transmitted between nodes in the network is transmitted over this common transmission medium and is able to be received by all nodes in the network simultaneously.

Distributed bus

The type of network topology in which all of the nodes of the network are connected to a common transmission medium which has more than two endpoints that are created by adding branches to the main section of the transmission medium the physical distributed bus topology functions in exactly the same fashion as the physical linear bus topology (i.e., all nodes share a common transmission medium).

Star

In local area networks with a star topology, each network host is connected to a central point with a point-to-point connection. In Star topology every node

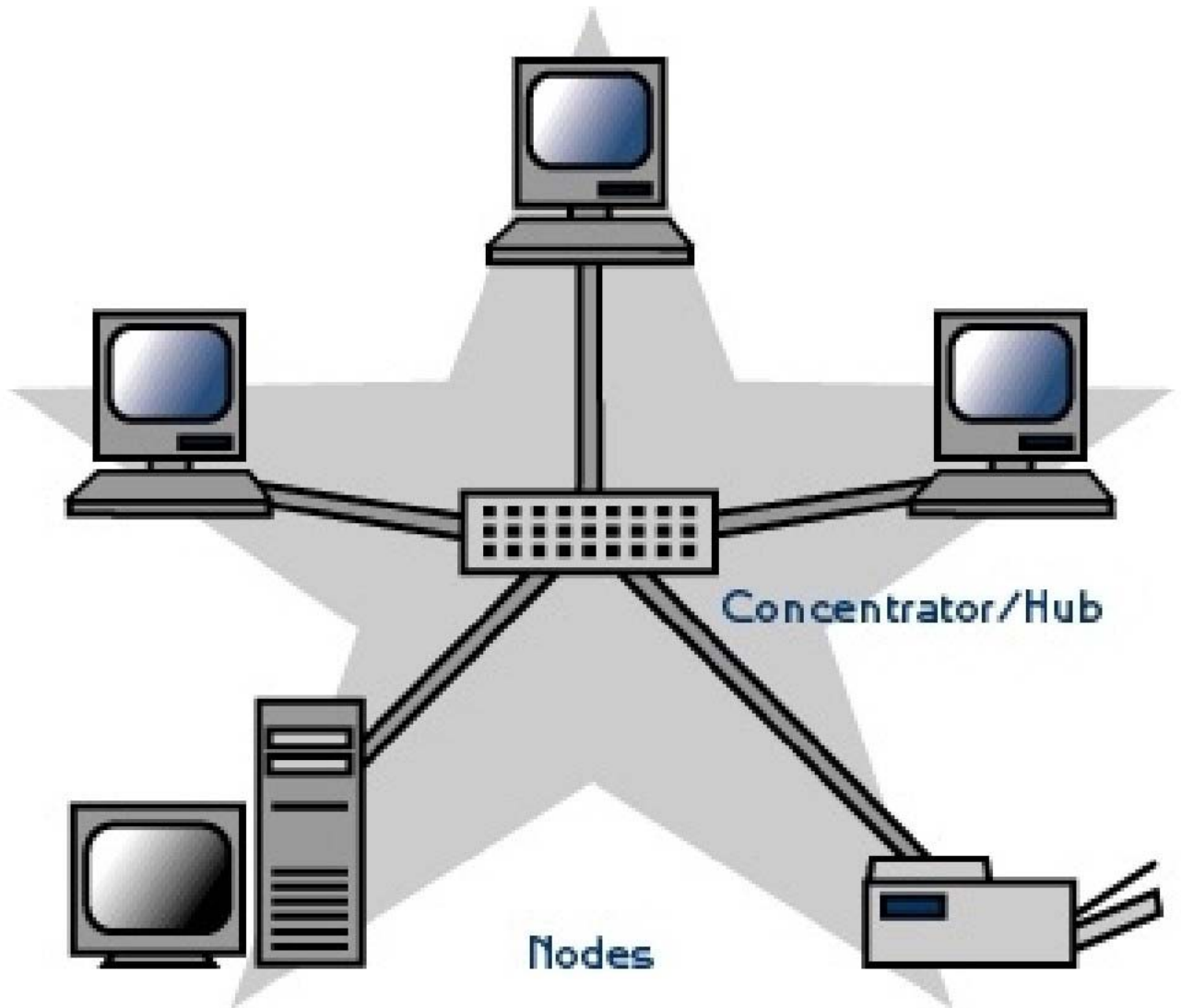
(computer workstation or any other peripheral) is connected to central node called hub or switch.

The switch is the server and the peripherals are the clients. The network does not necessarily have to resemble a star to be classified as a star network, but all of the nodes on the network must be connected to one central device.

All traffic that traverses the network passes through the central point. The central point acts as a signal repeater.

The star topology is considered the easiest topology to design and implement. An advantage of the star topology is the simplicity of adding additional nodes. The primary disadvantage of the star topology is that the central point represents a single point of failure.

Star Topology

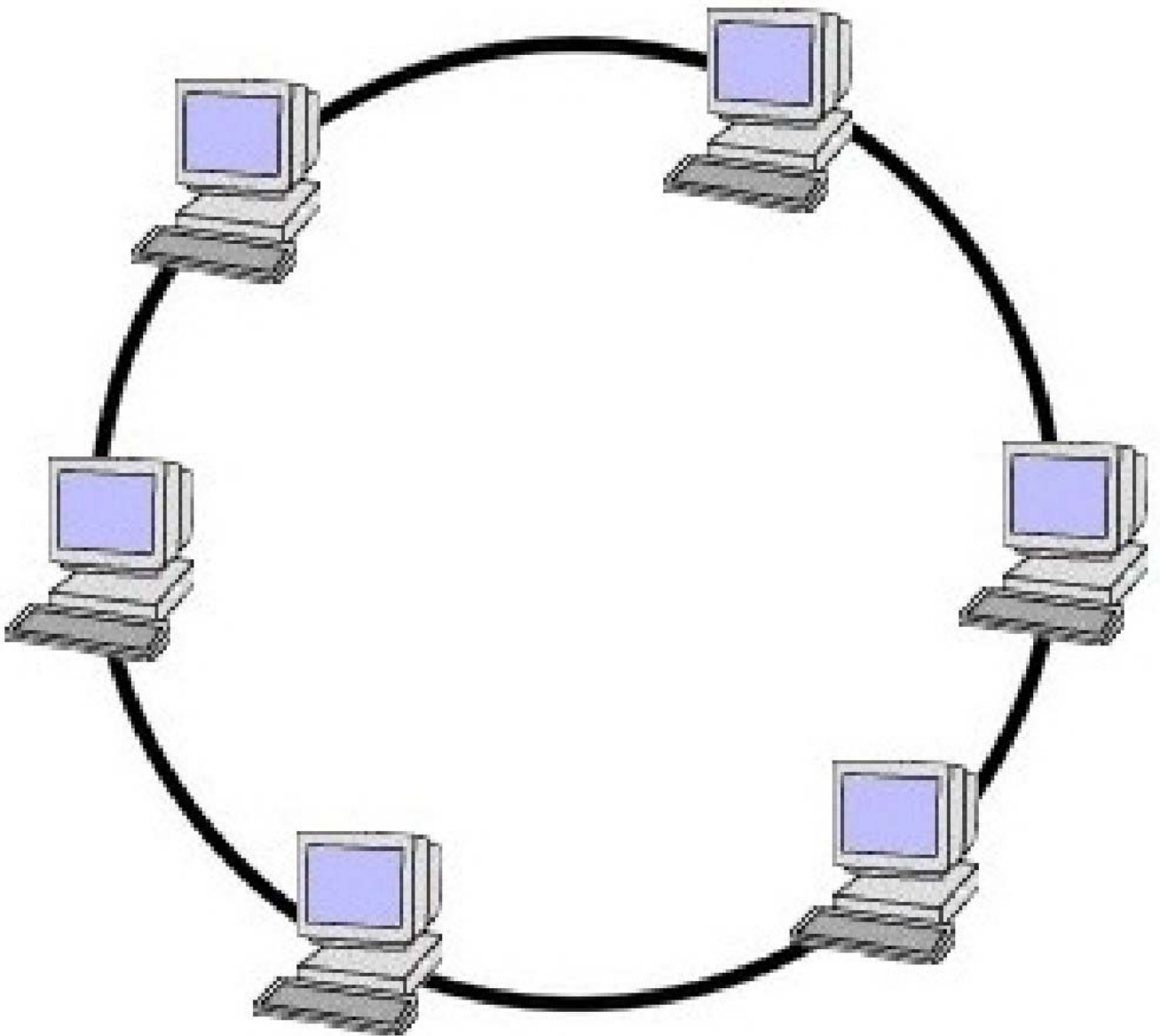


Ring

A network topology that is set up in a circular fashion in which data travels around the ring in one direction and each device on the ring acts as a repeater to keep the signal strong as it travels. Each device incorporates a receiver for the incoming signal and a transmitter to send the data on to the next device in the ring.

The network is dependent on the ability of the signal to travel around the ring. When a device sends data, it must travel through each device on the ring until it reaches its destination. Every node is a critical link. If one node goes down the whole link would be affected.

Ring Topology

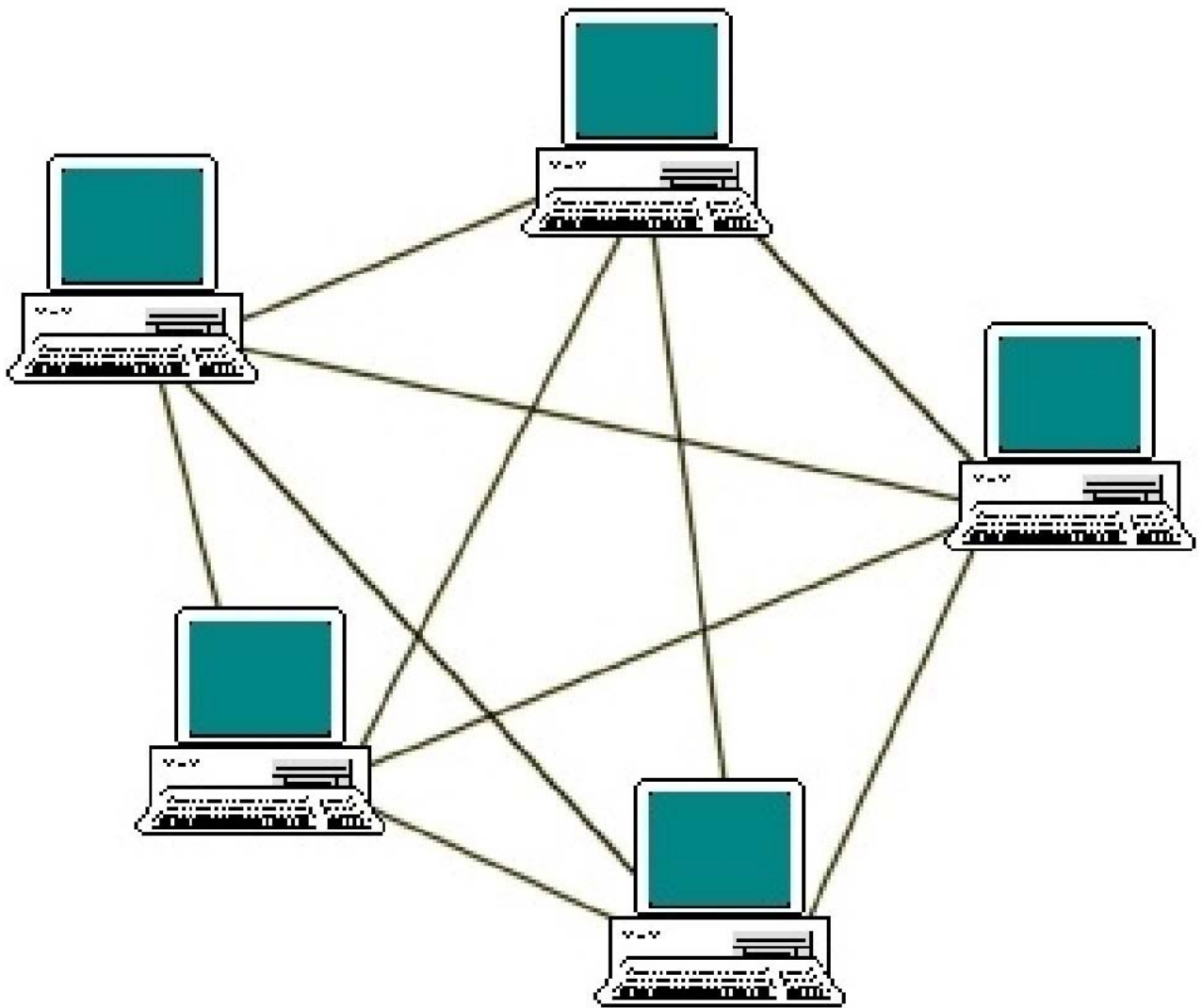


Mesh

The value of a fully meshed networks is proportional to the exponent of the number of subscribers, assuming that communicating groups of any two endpoints, up to and including all the endpoints, is approximated by Reed's Law.

A mesh network provides for high availability and redundancy. However, the cost of such network could be very expensive if dozens of devices are in the mesh.

Mesh Topology



Fully connected mesh topology

A fully connected network is a communication network in which each of the nodes is connected to each other. In graph theory it known as a complete graph. A fully connected network doesn't need to use switching nor broadcasting. However, its major disadvantage is that the number of connections grows quadratic ally with the number of nodes, so it is extremely impractical for large networks. A two-node network is technically a fully connected network.

Partially connected mesh topology

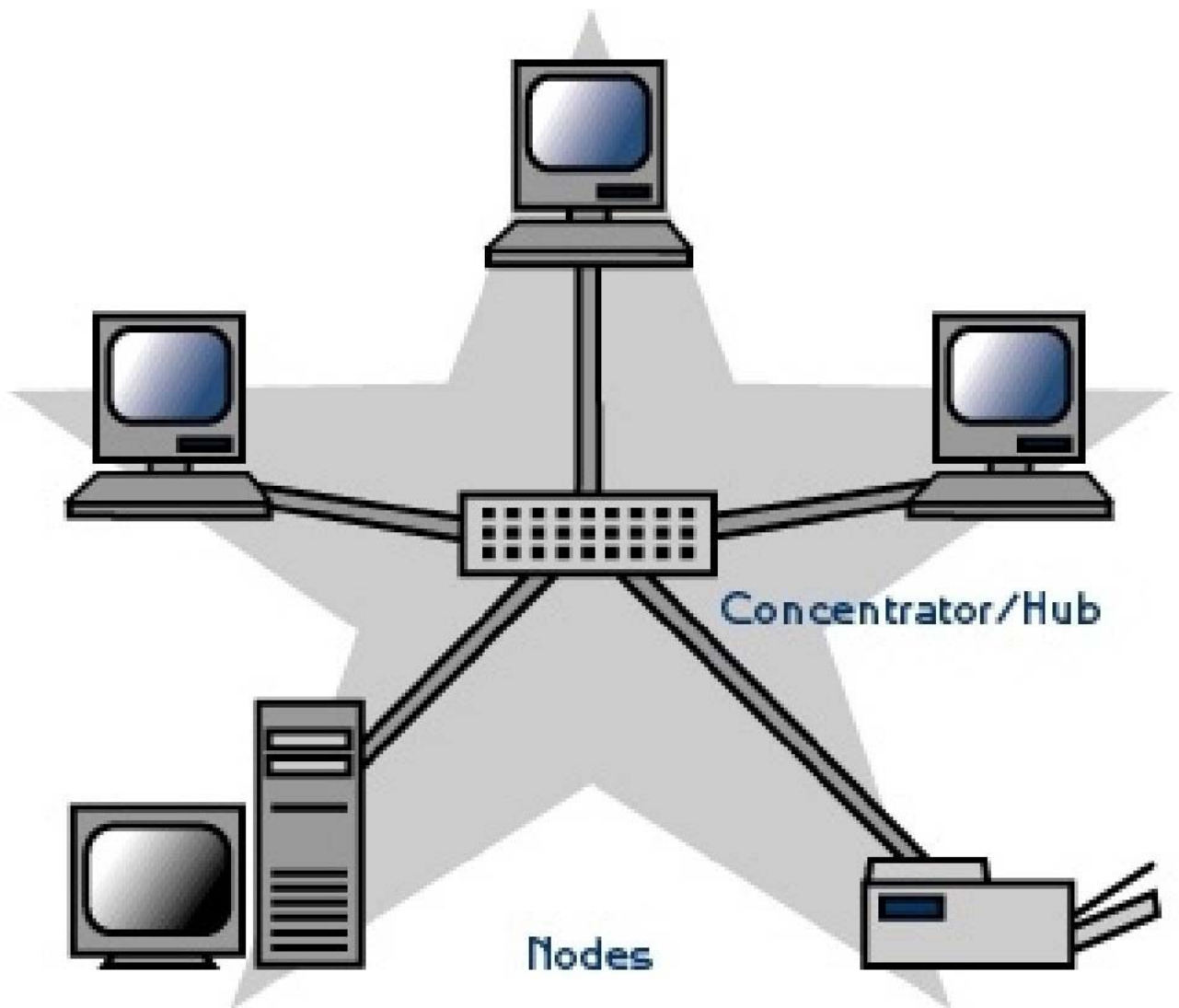
The type of network topology in which some of the nodes of the network are connected to more than one other node in the network with a point-to-point link this makes it possible to take advantage of some of the redundancy that is provided by a physical fully connected mesh topology without the expense and complexity required for a connection between every node in the network.

The following answers are incorrect:

The other options presented are not valid.
CISA review manual 2014, Page number 262

QUESTION 430

Identify the network topology from below diagram presented below:



Network Topology

- A. Bus
- B. Star
- C. Ring
- D. Mesh

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support For your exam you should know the information below related to LAN topologies:

LAN Topologies

Network topology is the physical arrangement of the various elements (links, nodes, etc.) of a computer network.

Essentially, it is the topological structure of a network, and may be depicted physically or logically. Physical topology refers to the placement of the network's various components, including device location and cable installation, while logical topology shows how data flows within a network, regardless of its physical design.

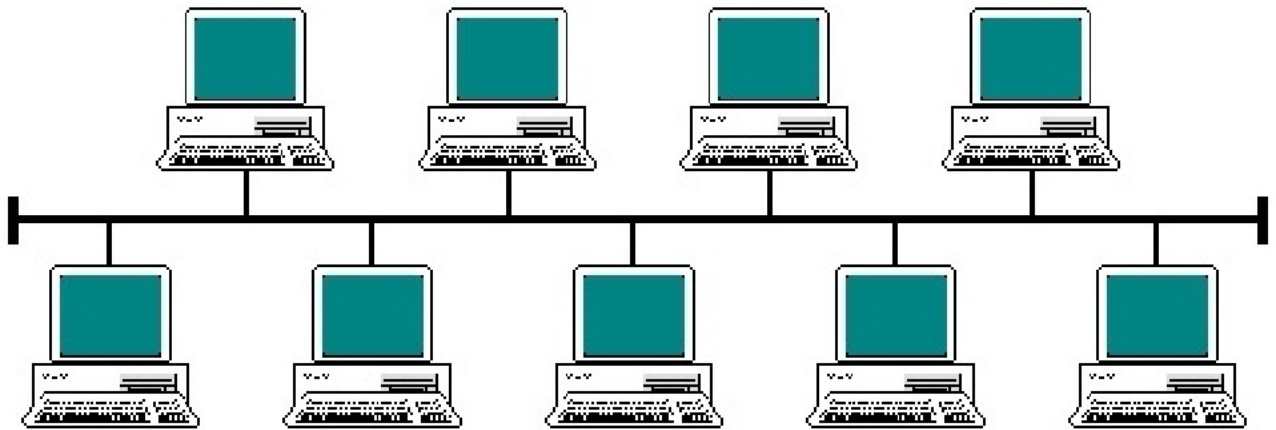
Distances between nodes, physical interconnections, transmission rates, and/or signal types may differ between two networks, yet their topologies may be identical.

Bus

In local area networks where bus topology is used, each node is connected to a single cable. Each computer or server is connected to the single bus cable. A signal from the source travels in both directions to all machines connected on the bus cable until it finds the intended recipient. If the machine address does not match the intended address for the data, the machine ignores the data. Alternatively, if the data matches the machine address, the data is accepted. Since the bus topology consists of only one wire, it is rather inexpensive to implement when compared to other topologies. However, the low cost of implementing the technology is offset by the high cost of managing the network. Additionally, since only one cable is utilized, it can be the single point of failure. If the network cable is terminated on both ends and when without termination data transfer stop and when cable breaks, the entire network will be down.

Bus topology

Graphic from:



Linear bus

The type of network topology in which all of the nodes of the network are connected to a common transmission medium which has exactly two endpoints (this is the 'bus', which is also commonly referred to as the backbone, or trunk) all data that is transmitted between nodes in the network is transmitted over this common transmission medium and is able to be received by all nodes in the network simultaneously.

Distributed bus

The type of network topology in which all of the nodes of the network are connected to a common transmission medium which has more than two endpoints that are created by adding branches to the main section of the transmission medium the physical distributed bus topology functions in exactly the same fashion as the physical linear bus topology (i.e., all nodes share a common transmission medium).

Star

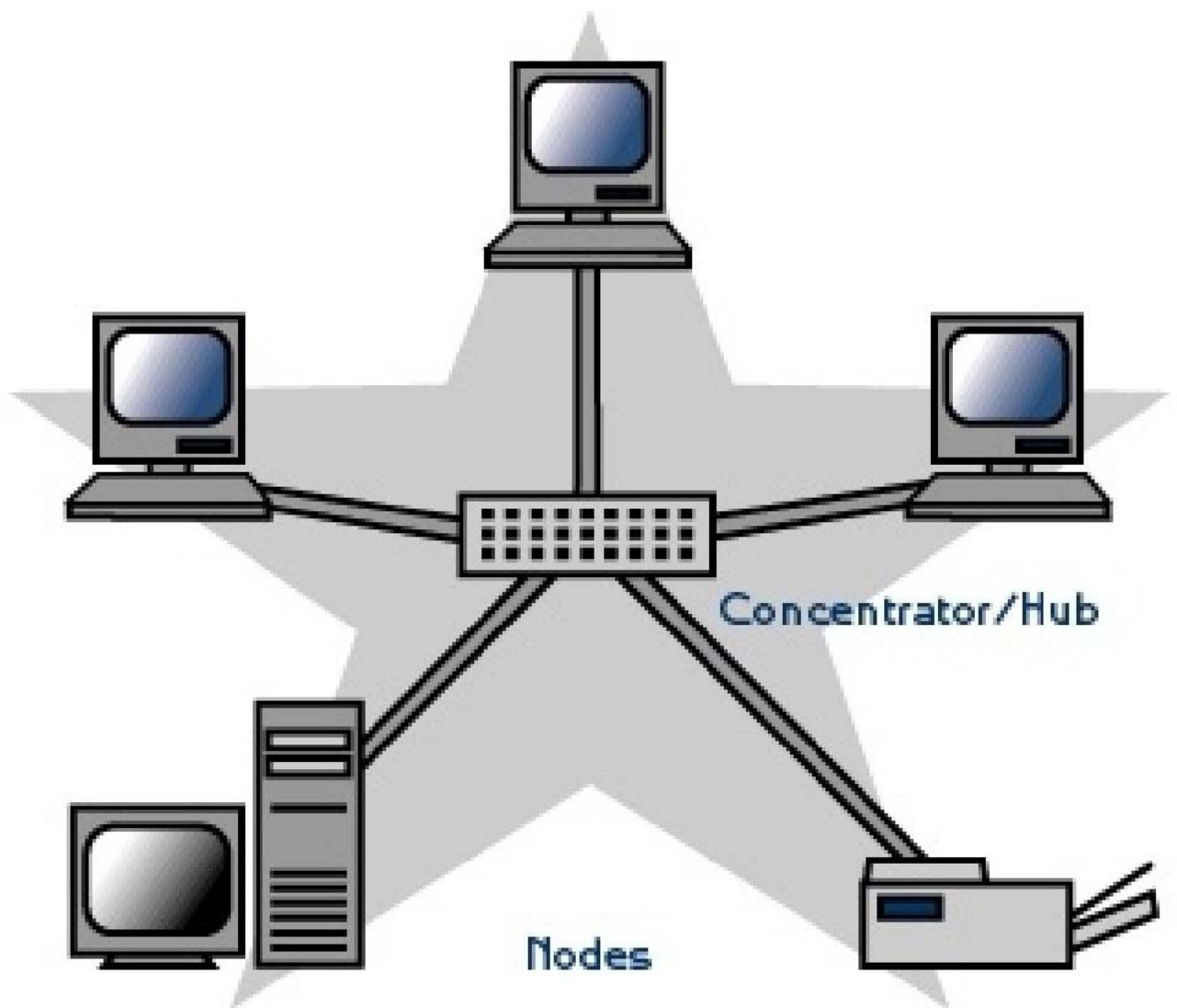
In local area networks with a star topology, each network host is connected to a central point with a point-to-point connection. In Star topology every node (computer workstation or any other peripheral) is connected to central node called hub or switch.

The switch is the server and the peripherals are the clients. The network does not necessarily have to resemble a star to be classified as a star network, but all of the nodes on the network must be connected to one central device.

All traffic that traverses the network passes through the central point. The central point acts as a signal repeater.

The star topology is considered the easiest topology to design and implement. An advantage of the star topology is the simplicity of adding additional nodes. The primary disadvantage of the star topology is that the central point represents a single point of failure.

Star Topology

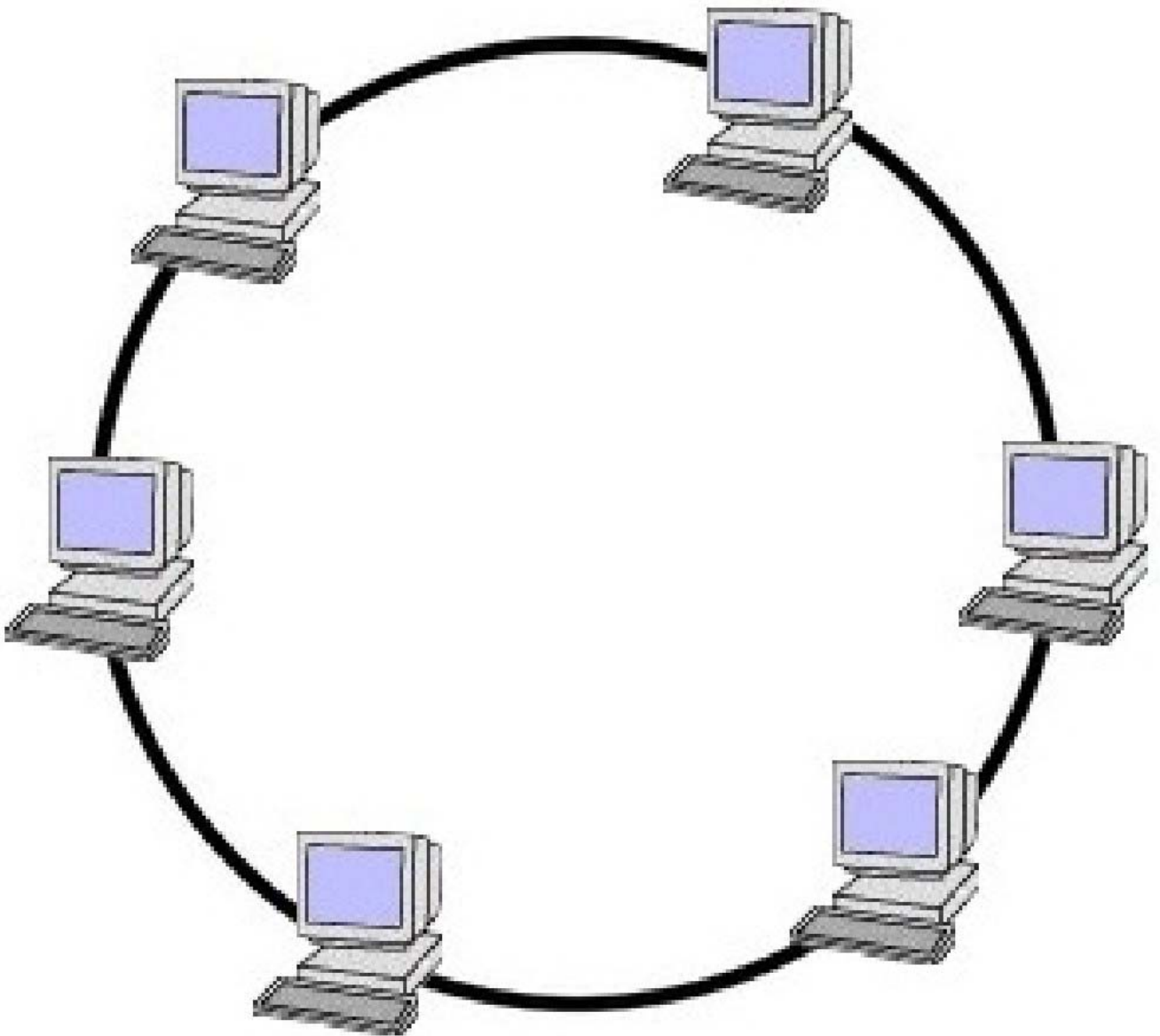


Ring

A network topology that is set up in a circular fashion in which data travels around the ring in one direction and each device on the ring acts as a repeater to keep the signal strong as it travels. Each device incorporates a receiver for the incoming signal and a transmitter to send the data on to the next device in the ring.

The network is dependent on the ability of the signal to travel around the ring. When a device sends data, it must travel through each device on the ring until it reaches its destination. Every node is a critical link. If one node goes down the whole link would be affected.

Ring Topology

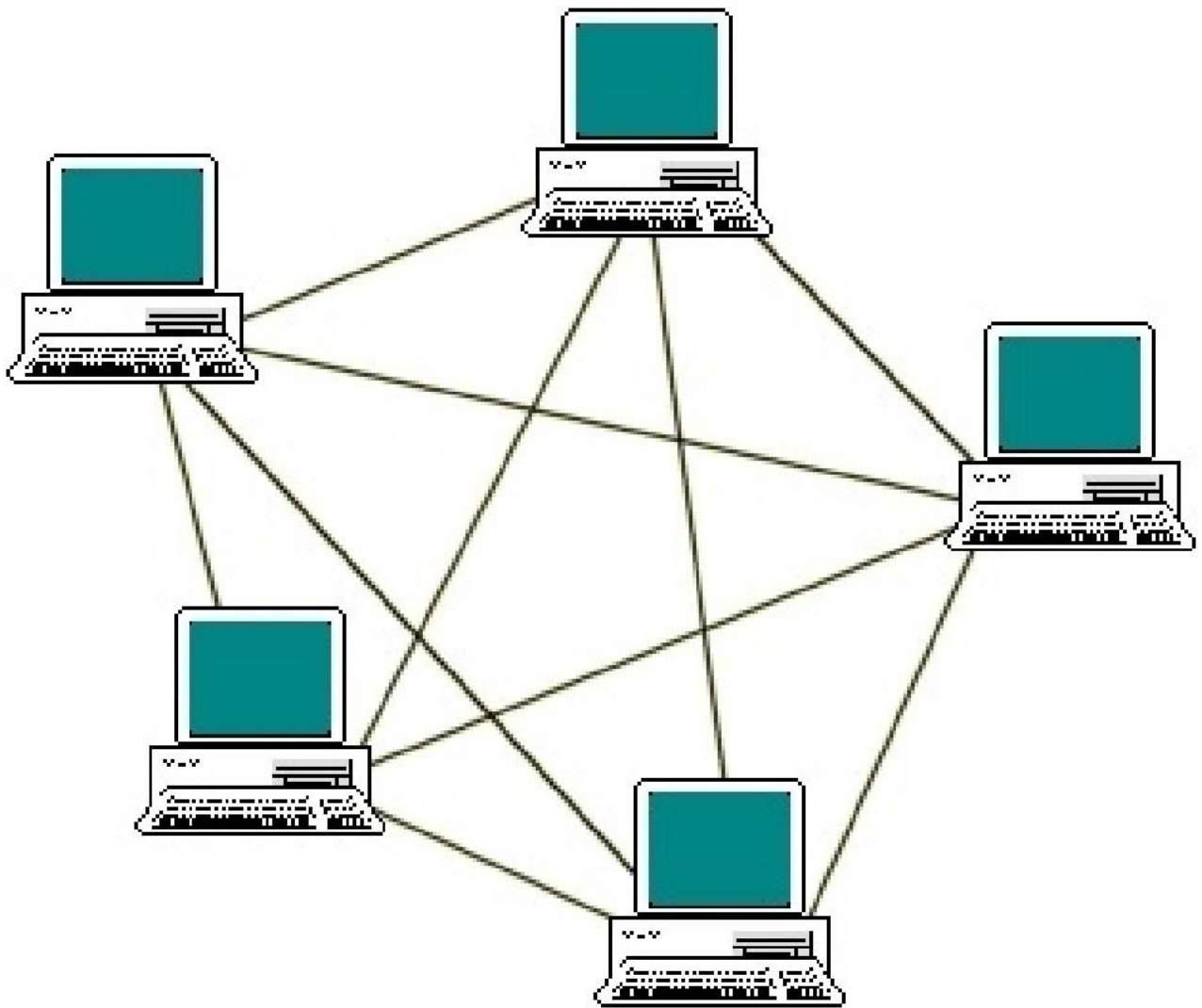


Mesh

The value of a fully meshed networks is proportional to the exponent of the number of subscribers, assuming that communicating groups of any two endpoints, up to and including all the endpoints, is approximated by Reed's Law.

A mesh network provides for high availability and redundancy. However, the cost of such network could be very expensive if dozens of devices are in the mesh.

Mesh Topology



Fully connected mesh topology

A fully connected network is a communication network in which each of the nodes is connected to each other. In graph theory it known as a complete graph. A fully connected network doesn't need to use switching nor broadcasting. However, its major disadvantage is that the number of connections grows quadratic ally with the number of nodes, so it is extremely impractical for large networks. A two-node network is technically a fully connected network.

Partially connected mesh topology

The type of network topology in which some of the nodes of the network are connected to more than one other node in the network with a point-to-point link this makes it possible to take advantage of some of the redundancy that is provided by a physical fully connected mesh topology without the expense and complexity required for a connection between every node in the network.

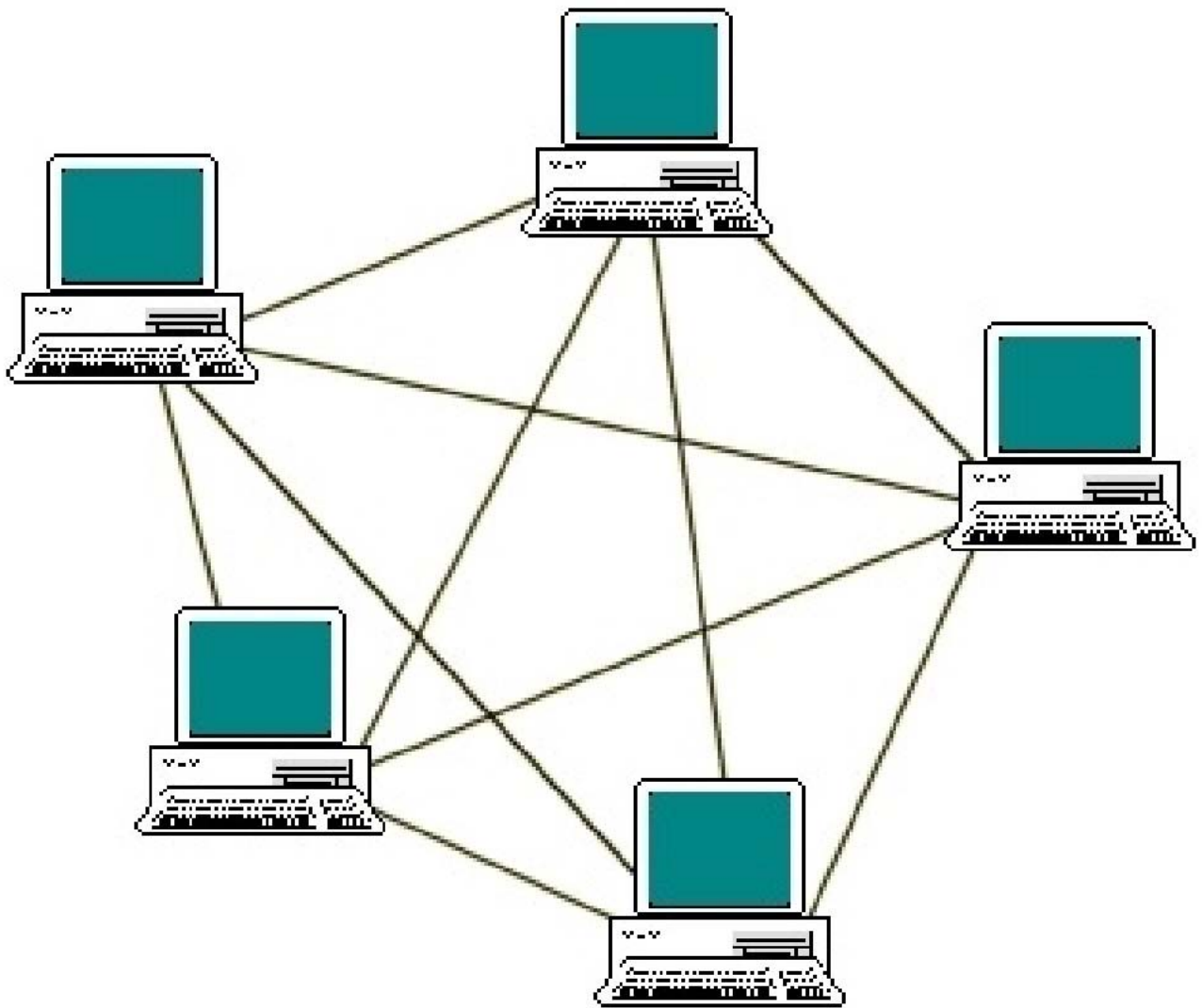
The following answers are incorrect:

The other options presented are not valid.

CISA review manual 2014, Page number 262

QUESTION 431

Identify the network topology from below diagram presented below:



Network Topology

- A. Bus
- B. Star
- C. Ring
- D. Mesh

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support For your exam you should know the information below related to LAN topologies:

LAN Topologies

Network topology is the physical arrangement of the various elements (links, nodes, etc.) of a computer network.

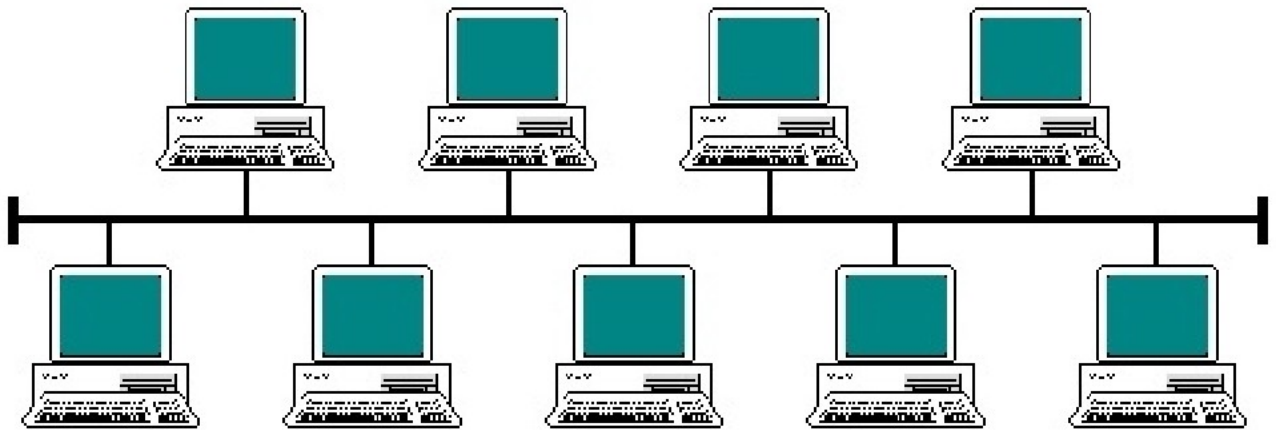
Essentially, it is the topological structure of a network, and may be depicted physically or logically. Physical topology refers to the placement of the network's various components, including device location and cable installation, while logical topology shows how data flows within a network, regardless of its physical design.

Distances between nodes, physical interconnections, transmission rates, and/or signal types may differ between two networks, yet their topologies may be identical.

Bus

In local area networks where bus topology is used, each node is connected to a single cable. Each computer or server is connected to the single bus cable. A signal from the source travels in both directions to all machines connected on the bus cable until it finds the intended recipient. If the machine address does not match the intended address for the data, the machine ignores the data. Alternatively, if the data matches the machine address, the data is accepted. Since the bus topology consists of only one wire, it is rather inexpensive to implement when compared to other topologies. However, the low cost of implementing the technology is offset by the high cost of managing the network. Additionally, since only one cable is utilized, it can be the single point of failure. If the network cable is terminated on both ends and when without termination data transfer stop and when cable breaks, the entire network will be down.

Bus topology



Linear bus

The type of network topology in which all of the nodes of the network are connected to a common transmission medium which has exactly two endpoints (this is the 'bus', which is also commonly referred to as the backbone, or trunk) all data that is transmitted between nodes in the network is transmitted over this common transmission medium and is able to be received by all nodes in the network simultaneously.

Distributed bus

The type of network topology in which all of the nodes of the network are connected to a common transmission medium which has more than two endpoints that are created by adding branches to the main section of the transmission medium the physical distributed bus topology functions in exactly the same fashion as the physical linear bus topology (i.e., all nodes share a common transmission medium).

Star

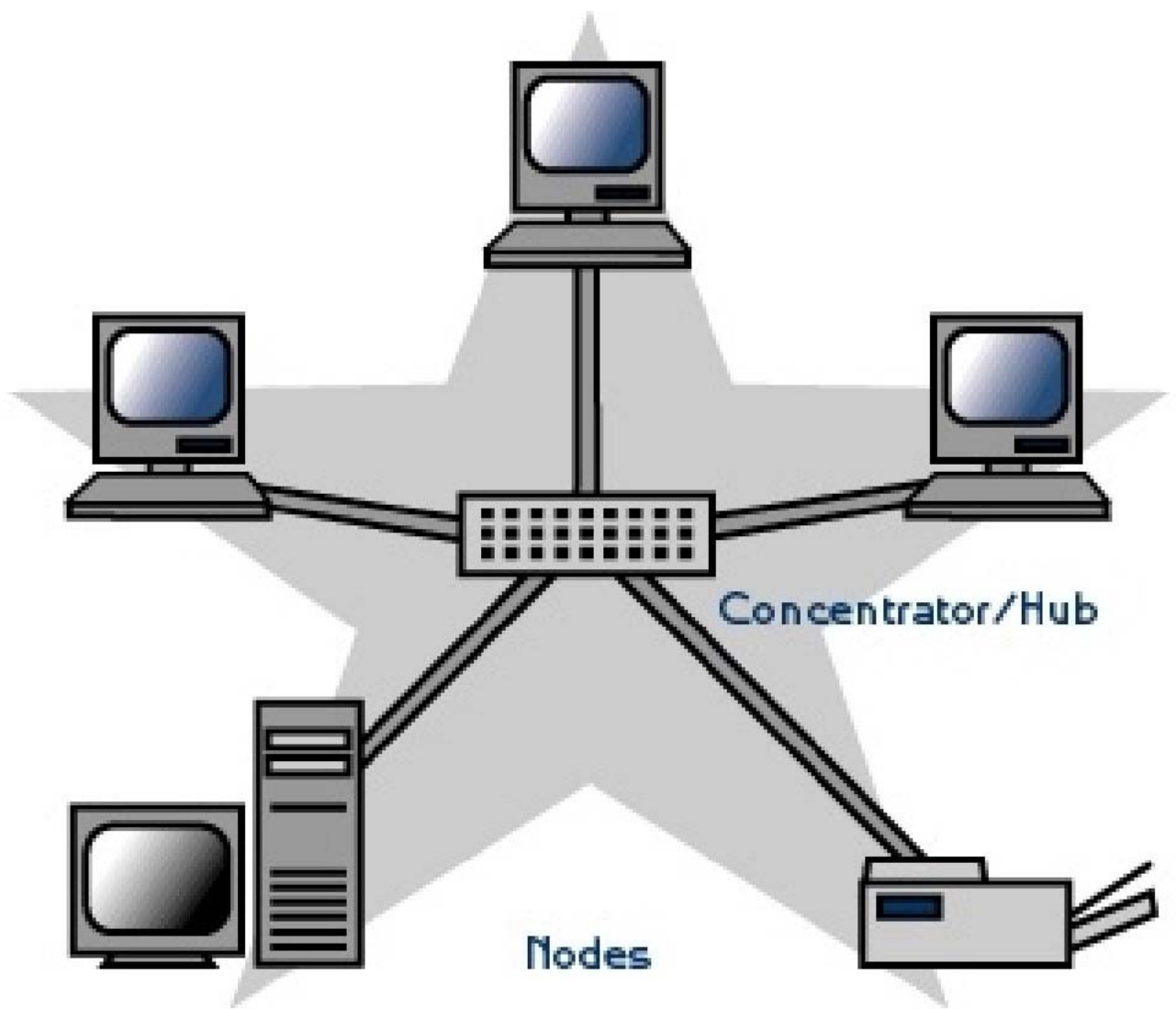
In local area networks with a star topology, each network host is connected to a central point with a point-to-point connection. In Star topology every node (computer workstation or any other peripheral) is connected to central node called hub or switch.

The switch is the server and the peripherals are the clients. The network does not necessarily have to resemble a star to be classified as a star network, but all of the nodes on the network must be connected to one central device.

All traffic that traverses the network passes through the central point. The central point acts as a signal repeater.

The star topology is considered the easiest topology to design and implement. An advantage of the star topology is the simplicity of adding additional nodes. The primary disadvantage of the star topology is that the central point represents a single point of failure.

Star Topology

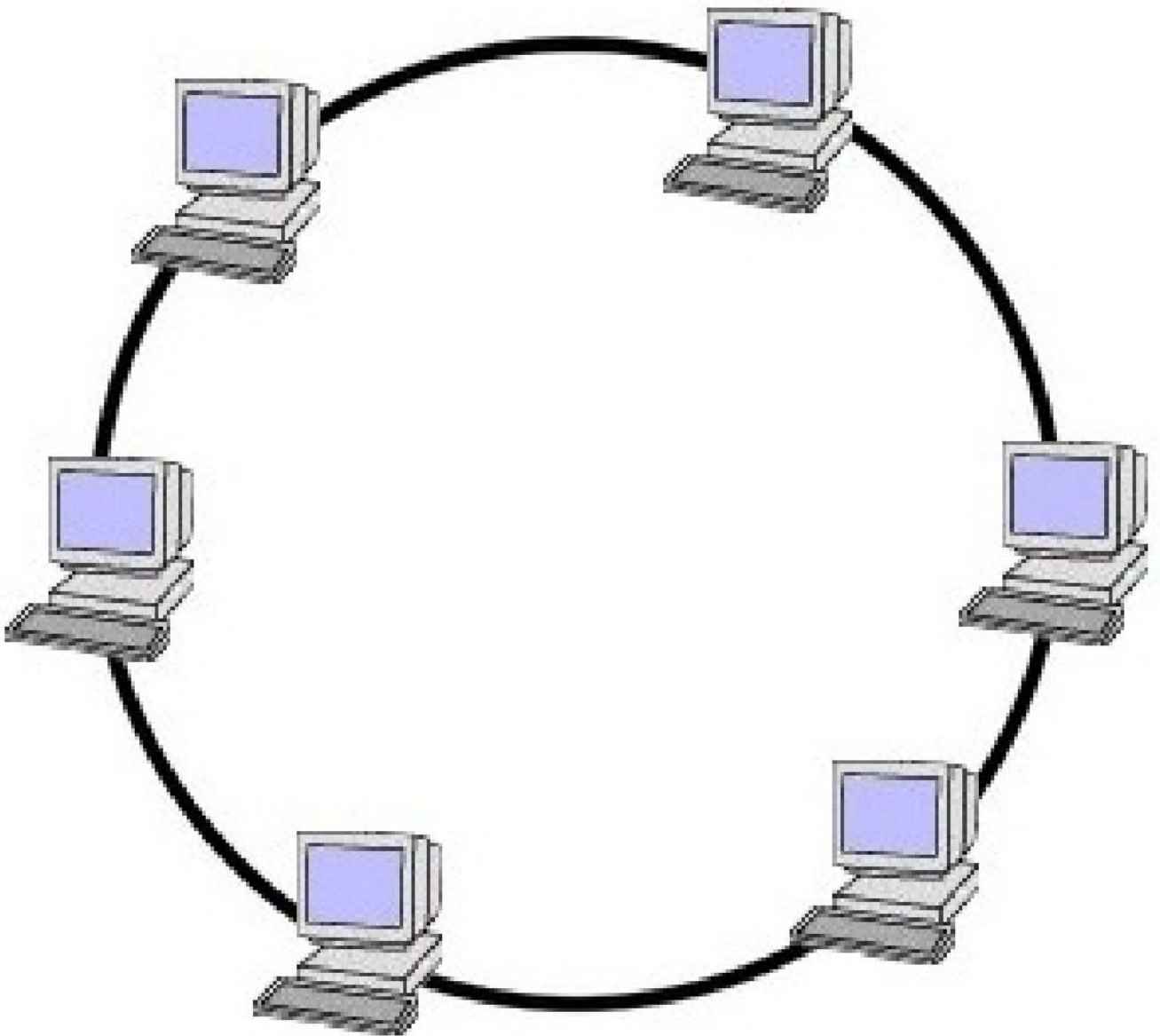


Ring

A network topology that is set up in a circular fashion in which data travels around the ring in one direction and each device on the ring acts as a repeater to keep the signal strong as it travels. Each device incorporates a receiver for the incoming signal and a transmitter to send the data on to the next device in the ring.

The network is dependent on the ability of the signal to travel around the ring. When a device sends data, it must travel through each device on the ring until it reaches its destination. Every node is a critical link. If one node goes down the whole link would be affected.

Ring Topology

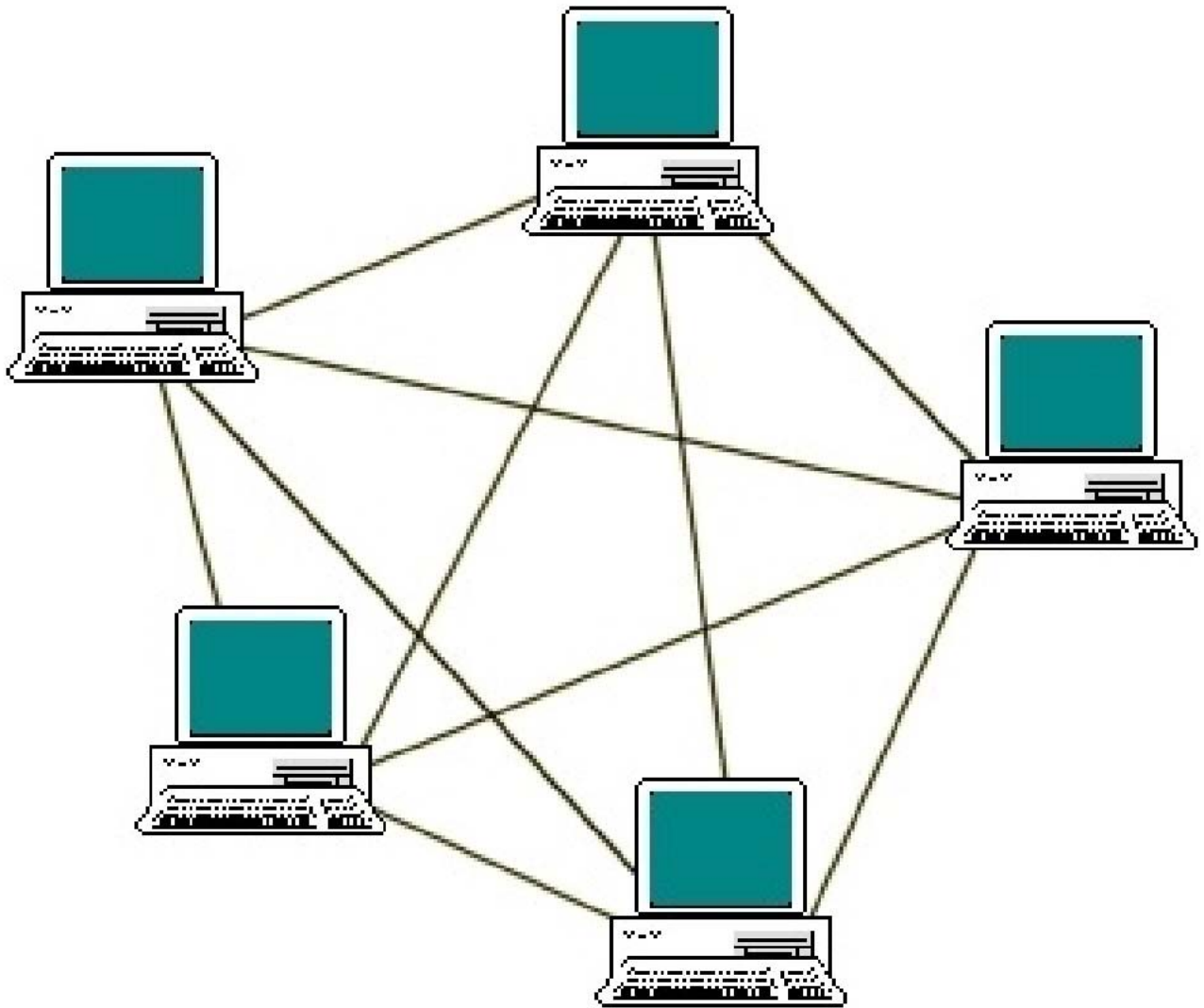


Mesh

The value of a fully meshed networks is proportional to the exponent of the number of subscribers, assuming that communicating groups of any two endpoints, up to and including all the endpoints, is approximated by Reed's Law.

A mesh network provides for high availability and redundancy. However, the cost of such network could be very expensive if dozens of devices are in the mesh.

Mesh Topology



Fully connected mesh topology

A fully connected network is a communication network in which each of the nodes is connected to each other. In graph theory it known as a complete graph. A fully connected network doesn't need to use switching nor broadcasting. However, its major disadvantage is that the number of connections grows quadratic ally with the number of nodes, so it is extremely impractical for large networks. A two-node network is technically a fully connected network.

Partially connected mesh topology

The type of network topology in which some of the nodes of the network are connected to more than one other node in the network with a point-to-point link this makes it possible to take advantage of some of the redundancy that is provided by a physical fully connected mesh topology without the expense and complexity required for a connection between every node in the network.

The following answers are incorrect:

The other options presented are not valid.

CISA review manual 2014, Page number 262

QUESTION 432

Identify the WAN message switching technique being used from the description presented below:

"Data is routed in its entirety from the source node to the destination node, one hope at a time. During message routing, every intermediate switch in the network stores the whole message. If the entire network's resources are engaged or the network becomes blocked, this WAN switching technology stores and delays the message until ample resources become available for effective transmission of the message. "

- A. Message Switching
- B. Packet switching
- C. Circuit switching
- D. Virtual Circuits

Correct Answer: A

Explanation

Explanation/Reference:

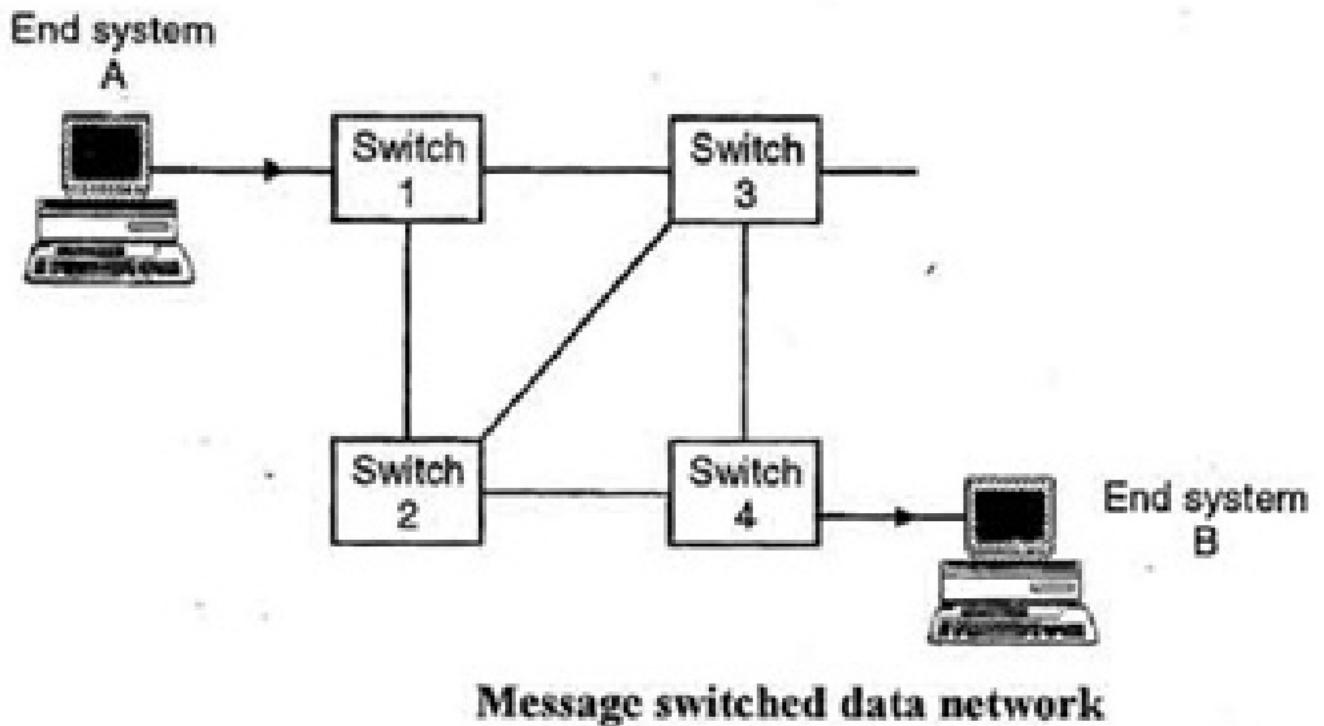
Section: Information System Operations, Maintenance and Support For your exam you should know below information about WAN message transmission technique:

Message Switching

Message switching is a network switching technique in which data is routed in its entirety from the source node to the destination node, one hope at a time. During

message routing, every intermediate switch in the network stores the whole message. If the entire network's resources are engaged or the network becomes blocked, the message-switched network stores and delays the message until ample resources become available for effective transmission of the message.

Message Switching

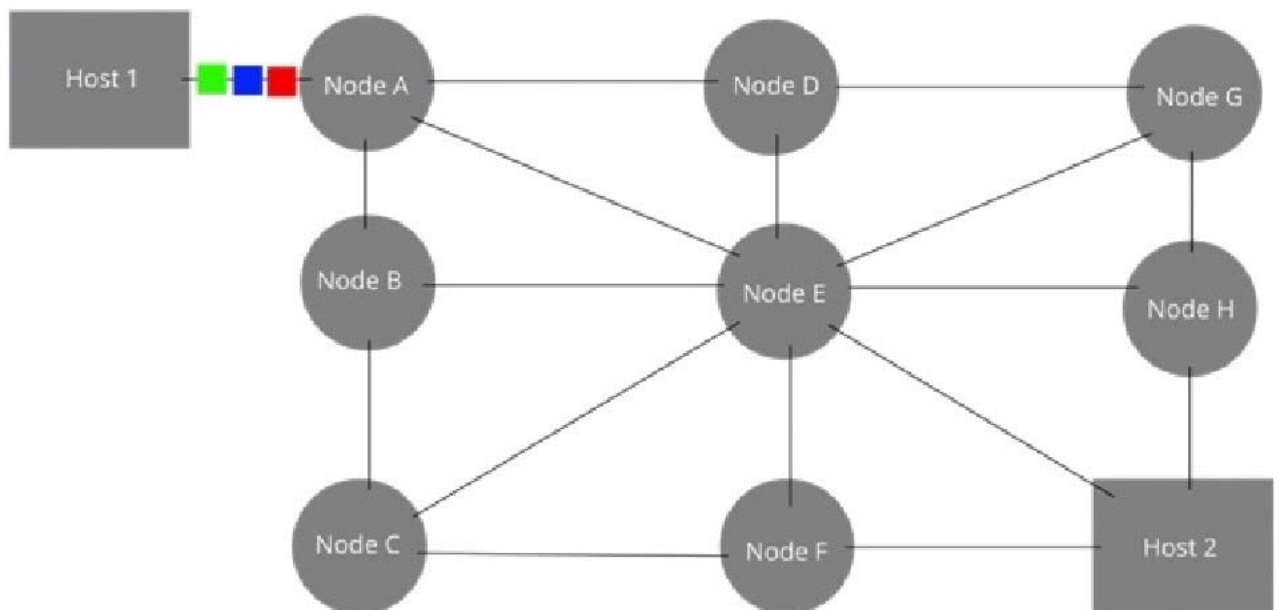


Packet Switching

Refers to protocols in which messages are divided into packets before they are sent. Each packet is then transmitted individually and can even follow different routes to its destination. Once all the packets forming a message arrive at the destination, they are recompiled into the original message.

Packet Switching

The original message is Green, Blue, Red.



Circuit Switching

Circuit switching is a methodology of implementing a telecommunications network in which two network nodes establish a dedicated communications channel (circuit) through the network before the nodes may communicate.

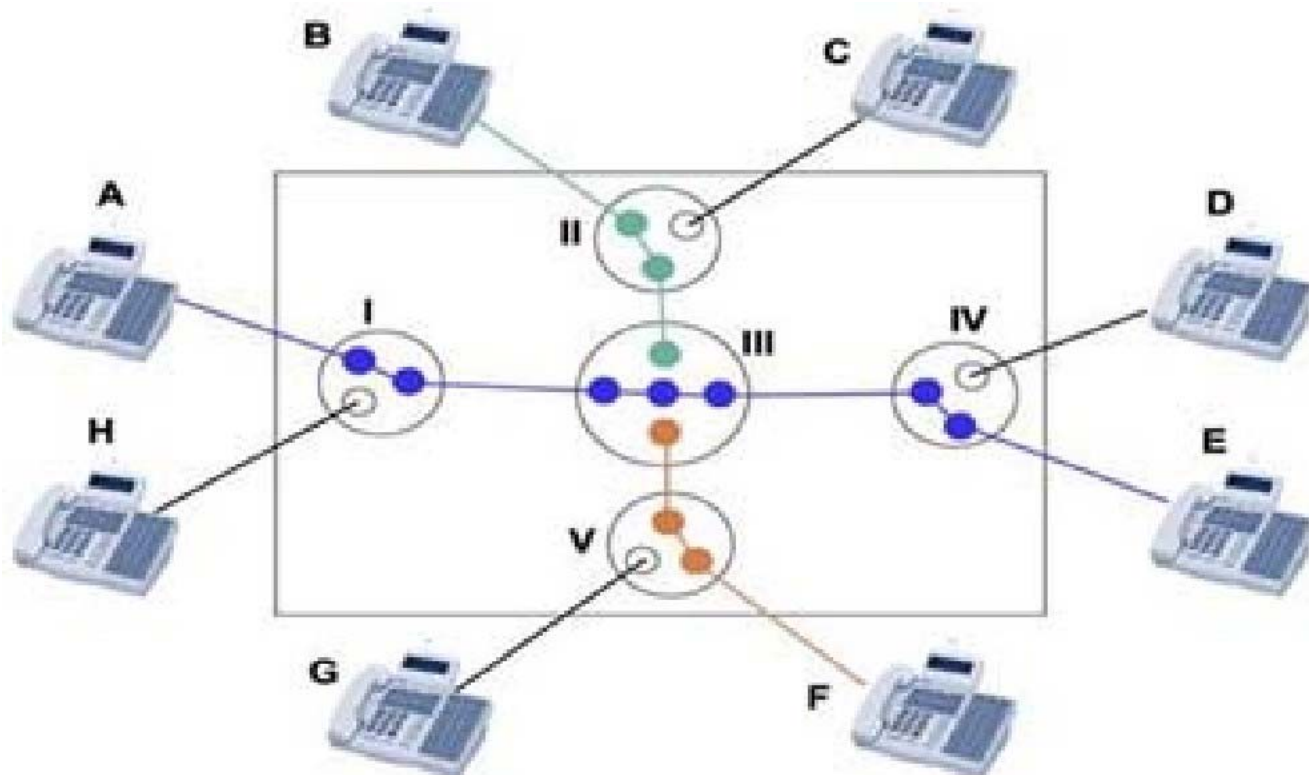
The circuit guarantees the full bandwidth of the channel and remains connected for the duration of the session. The circuit functions as if the nodes were physically connected similar to an electrical circuit. The defining example of a circuit-switched network is the early analog telephone network. When a call is made from one

telephone to another, switches within the telephone exchanges create a continuous wire circuit between the two telephones, for as long as the call lasts.

In circuit switching, the bit delay is constant during a connection, as opposed to packet switching, where

packet queues may cause varying and potentially indefinitely long packet transfer delays. No circuit can be degraded by competing users because it is protected from use by other callers until the circuit is released and a new connection is set up. Even if no actual communication is taking place, the channel remains reserved and protected from competing users.

Circuit Switching



See a table below comparing Circuit Switched versus Packet Switched networks:
Difference between Circuit and packet switching

	Circuit Switching	Packet Switching
Dedicated “copper” path	Yes	No
Bandwidth available	Fixed	Dynamic
Potentially wasted bandwidth	Yes	No
Store-and-forward-transmission	No	Yes
Each packet follows the same route	Yes	No
Call setup	Required	Not required
When can congestion occur	At setup time	On every packet
Charging	Per minute	Per packet

Virtual circuit

In telecommunications and computer networks, a virtual circuit (VC), synonymous with virtual connection and virtual channel, is a connection oriented communication service that is delivered by means of packet mode communication.

After a connection or virtual circuit is established between two nodes or application processes, a bit stream or byte stream may be delivered between the nodes; a virtual circuit protocol allows higher level protocols to avoid dealing with the division of data into segments, packets, or frames.

Virtual circuit communication resembles circuit switching, since both are connection oriented, meaning that in both cases data is delivered in correct order, and signaling overhead is required during a connection establishment phase. However, circuit switching provides constant bit rate and latency, while these may vary in

a virtual circuit service due to factors such as:

varying packet queue lengths in the network nodes,
varying bit rate generated by the application,
varying load from other users sharing the same network resources by means of statistical multiplexing, etc.

The following were incorrect answers:

The other options presented are not valid choices.

CISA review manual 2014 Page number 265

QUESTION 433

In which of the following WAN message transmission technique messages are divided into packets before they are sent and each packet is then transmitted individually and can even follow different routes to its destination?

- A. Message Switching
- B. Packet switching
- C. Circuit switching
- D. Virtual Circuits

Correct Answer: B

Explanation

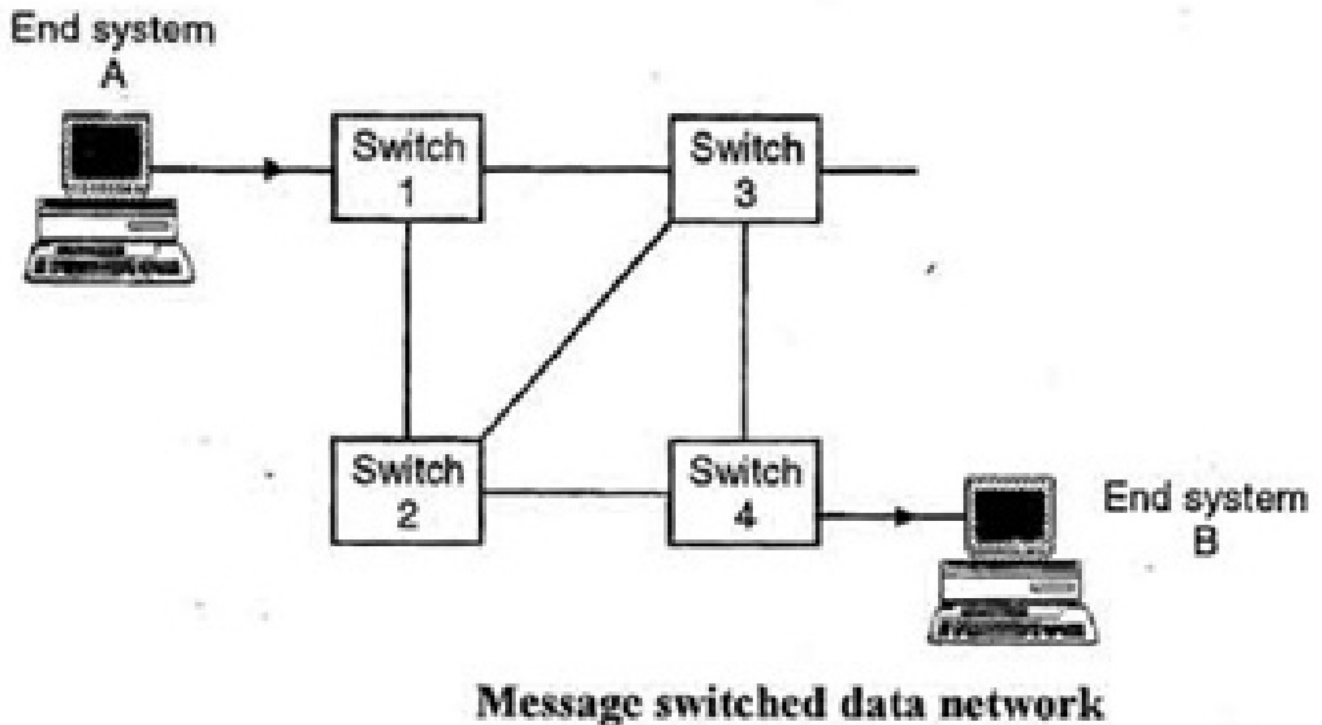
Explanation/Reference:

Section: Information System Operations, Maintenance and Support For your exam you should know below information about WAN message transmission technique:

Message Switching

Message switching is a network switching technique in which data is routed in its entirety from the source node to the destination node, one hop at a time. During message routing, every intermediate switch in the network stores the whole message. If the entire network's resources are engaged or the network becomes blocked, the message-switched network stores and delays the message until ample resources become available for effective transmission of the message.

Message Switching

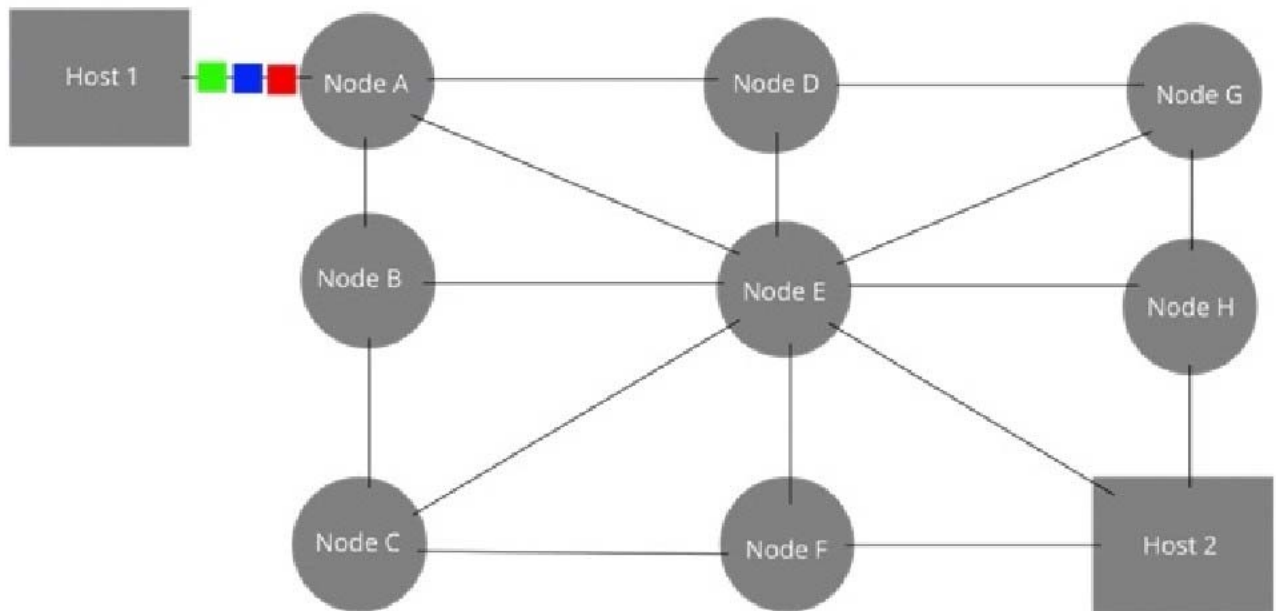


Packet Switching

Refers to protocols in which messages are divided into packets before they are sent. Each packet is then transmitted individually and can even follow different routes to its destination. Once all the packets forming a message arrive at the destination, they are recompiled into the original message.

Packet Switching

The original message is **Green**, **Blue**, **Red**.



Circuit Switching

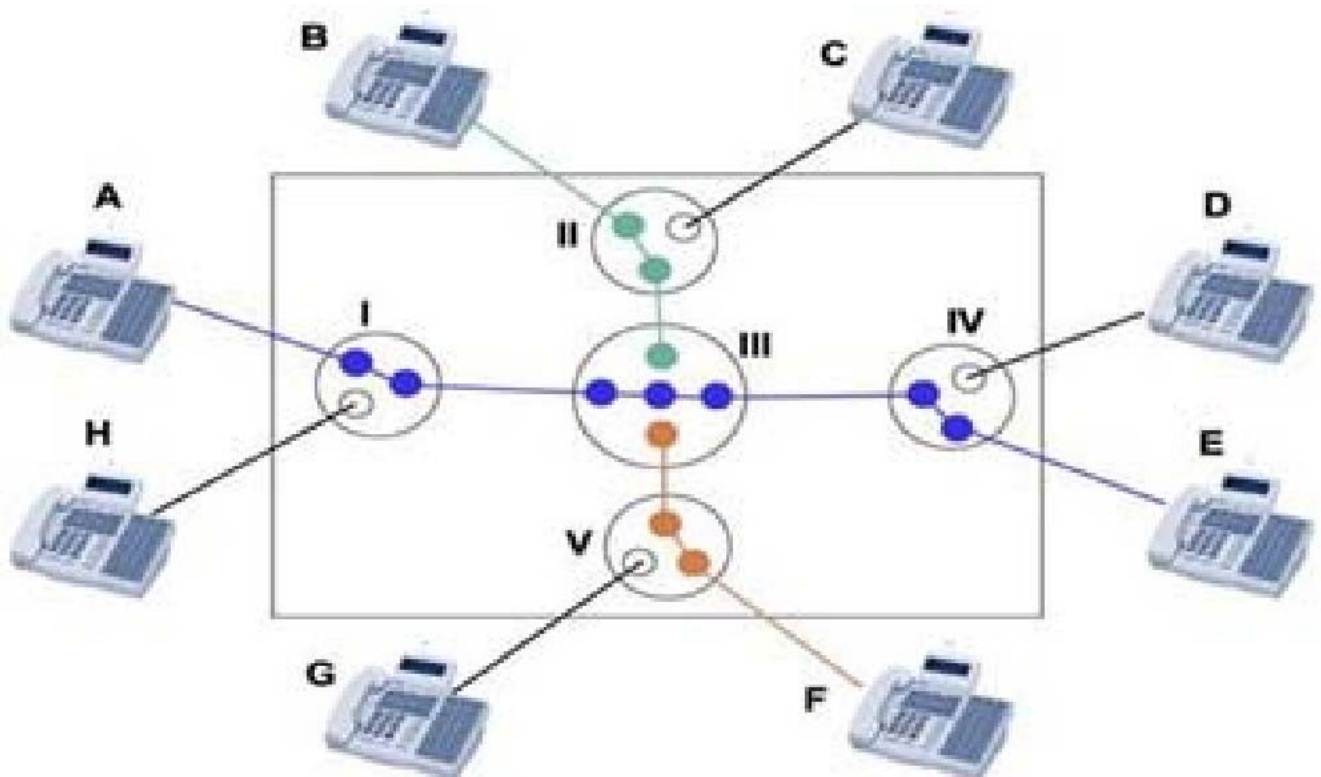
Circuit switching is a methodology of implementing a telecommunications network in which two network nodes establish a dedicated communications channel (circuit) through the network before the nodes may communicate.

The circuit guarantees the full bandwidth of the channel and remains connected for the duration of the session. The circuit functions as if the nodes were physically connected similar to an electrical circuit.

The defining example of a circuit-switched network is the early analog telephone network. When a call is made from one telephone to another, switches within the telephone exchanges create a continuous wire circuit between the two telephones, for as long as the call lasts.

In circuit switching, the bit delay is constant during a connection, as opposed to packet switching, where packet queues may cause varying and potentially indefinitely long packet transfer delays. No circuit can be degraded by competing users because it is protected from use by other callers until the circuit is released and a new connection is set up. Even if no actual communication is taking place, the channel remains reserved and protected from competing users.

Circuit Switching



See a table below comparing Circuit Switched versus Packet Switched networks:

Difference between Circuit and packet switching

	Circuit Switching	Packet Switching
Dedicated “copper” path	Yes	No
Bandwidth available	Fixed	Dynamic
Potentially wasted bandwidth	Yes	No
Store-and-forward-transmission	No	Yes
Each packet follows the same route	Yes	No
Call setup	Required	Not required
When can congestion occur	At setup time	On every packet
Charging	Per minute	Per packet

Virtual circuit

In telecommunications and computer networks, a virtual circuit (VC), synonymous with virtual connection and virtual channel, is a connection oriented communication service that is delivered by means of packet mode communication.

After a connection or virtual circuit is established between two nodes or application processes, a bit stream or byte stream may be delivered between the nodes; a virtual circuit protocol allows higher level protocols to avoid dealing with the division of data into segments, packets, or frames.

Virtual circuit communication resembles circuit switching, since both are connection oriented, meaning that in both cases data is delivered in correct order, and signaling overhead is required during a connection establishment phase. However, circuit switching provides constant bit rate and latency, while these may vary in a virtual circuit service due to factors such as:

varying packet queue lengths in the network nodes,
varying bit rate generated by the application,
varying load from other users sharing the same network resources by means of statistical multiplexing, etc.

The following were incorrect answers:

The other options presented are not valid choices.

CISA review manual 2014 Page number 265

QUESTION 434

In which of the following WAN message transmission technique does two network nodes establish a dedicated communications channel through the network before the nodes may communicate?

- A. Message Switching
- B. Packet switching
- C. Circuit switching
- D. Virtual Circuits

Correct Answer: C

Explanation

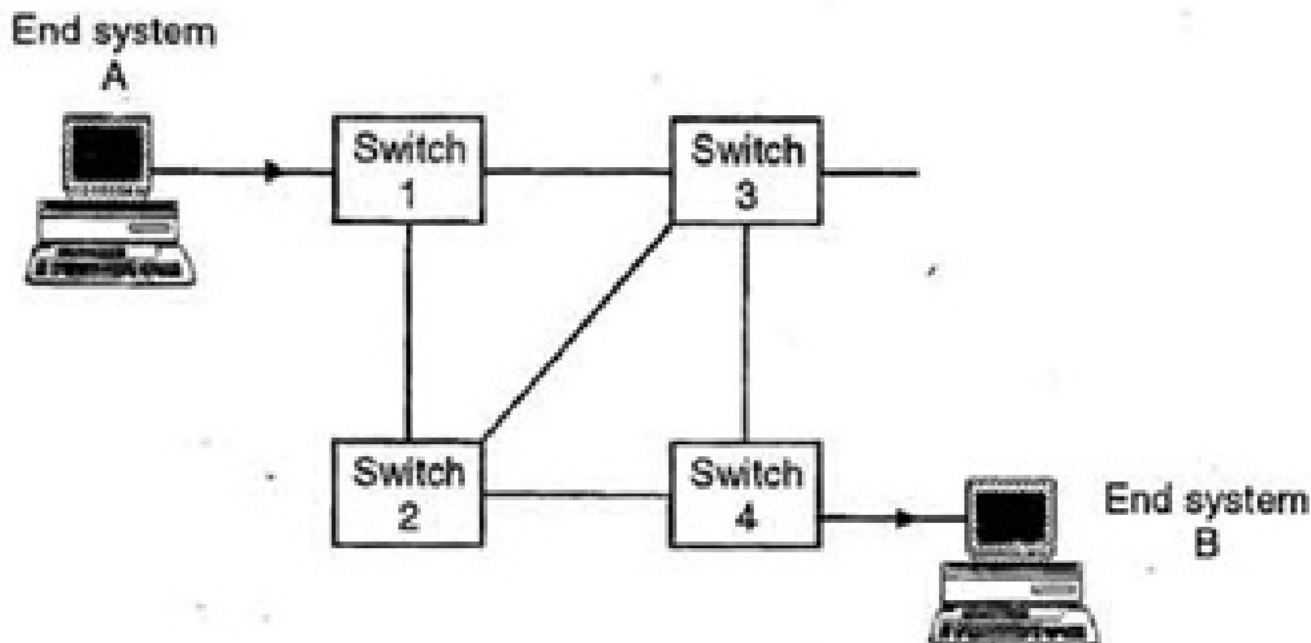
Explanation/Reference:

Section: Information System Operations, Maintenance and Support For your exam you should know below information about WAN message transmission technique:

Message Switching

Message switching is a network switching technique in which data is routed in its entirety from the source node to the destination node, one hop at a time. During message routing, every intermediate switch in the network stores the whole message. If the entire network's resources are engaged or the network becomes blocked, the message-switched network stores and delays the message until ample resources become available for effective transmission of the message.

Message Switching



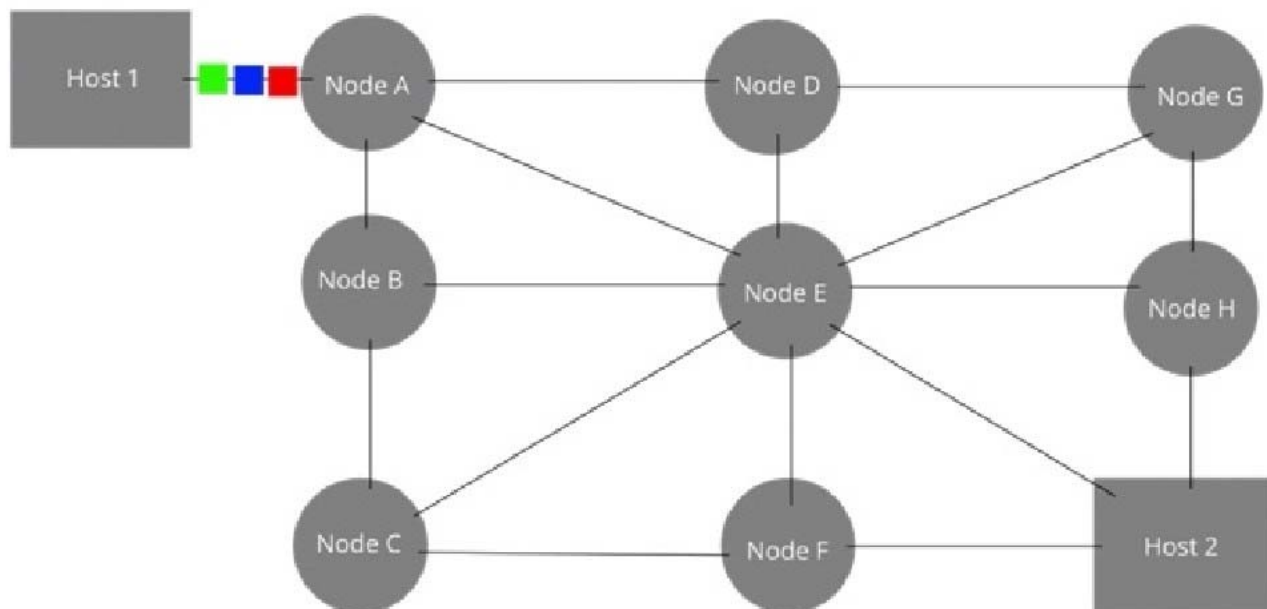
Message switched data network

Packet Switching

Refers to protocols in which messages are divided into packets before they are sent. Each packet is then transmitted individually and can even follow different routes to its destination. Once all the packets forming a message arrive at the destination, they are recompiled into the original message.

Packet Switching

The original message is **Green**, **Blue**, **Red**.



Circuit Switching

Circuit switching is a methodology of implementing a telecommunications network in which two network nodes establish a dedicated communications channel (circuit) through the network before the nodes may communicate.

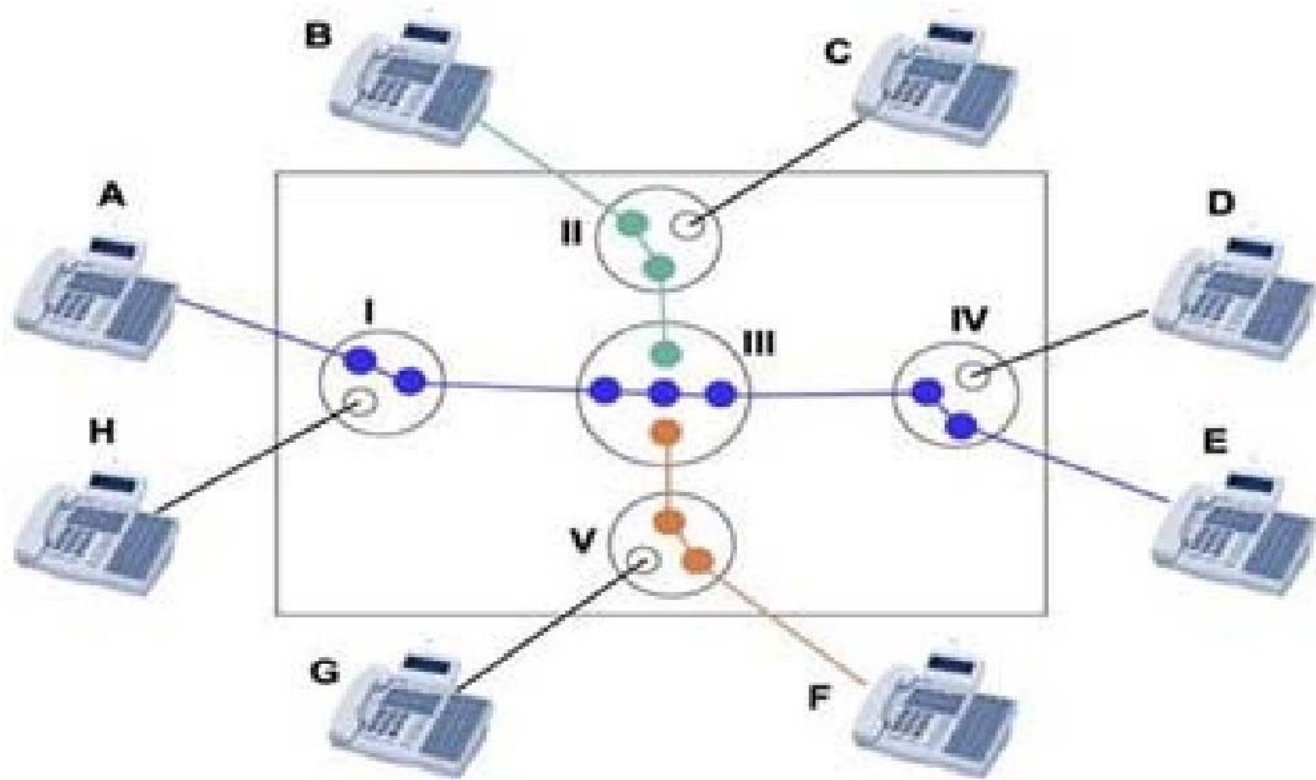
The circuit guarantees the full bandwidth of the channel and remains connected for the duration of the session.

The circuit functions as if the nodes were physically connected similar to an electrical circuit.

The defining example of a circuit-switched network is the early analog telephone network. When a call is made from one telephone to another, switches within the telephone exchanges create a continuous wire circuit between the two telephones, for as long as the call lasts.

In circuit switching, the bit delay is constant during a connection, as opposed to packet switching, where packet queues may cause varying and potentially indefinitely long packet transfer delays. No circuit can be degraded by competing users because it is protected from use by other callers until the circuit is released and a new connection is set up. Even if no actual communication is taking place, the channel remains reserved and protected from competing users.

Circuit Switching



See a table below comparing Circuit Switched versus Packet Switched networks:
Difference between Circuit and packet switching

	Circuit Switching	Packet Switching
Dedicated “copper” path	Yes	No
Bandwidth available	Fixed	Dynamic
Potentially wasted bandwidth	Yes	No
Store-and-forward-transmission	No	Yes
Each packet follows the same route	Yes	No
Call setup	Required	Not required
When can congestion occur	At setup time	On every packet
Charging	Per minute	Per packet

Virtual circuit
In telecommunications and computer networks, a virtual circuit (VC), synonymous with virtual connection and

virtual channel, is a connection oriented communication service that is delivered by means of packet mode communication.

After a connection or virtual circuit is established between two nodes or application processes, a bit stream or byte stream may be delivered between the nodes; a virtual circuit protocol allows higher level protocols to avoid dealing with the division of data into segments, packets, or frames.

Virtual circuit communication resembles circuit switching, since both are connection oriented, meaning that in both cases data is delivered in correct order, and signaling overhead is required during a connection establishment phase. However, circuit switching provides constant bit rate and latency, while these may vary in a virtual circuit service due to factors such as:

varying packet queue lengths in the network nodes,

varying bit rate generated by the application,
varying load from other users sharing the same network resources by means of statistical multiplexing, etc.

The following were incorrect answers:

The other options presented are not valid choices.

CISA review manual 2014 Page number 265

QUESTION 435

Which of the following statement INCORRECTLY describes circuit switching technique?

- A. Packet uses many different dynamic paths to get the same destination
- B. Connection oriented virtual links
- C. Fixed delays
- D. Traffic travels in a predictable and constant manner

Correct Answer: A

Explanation

Explanation/Reference:

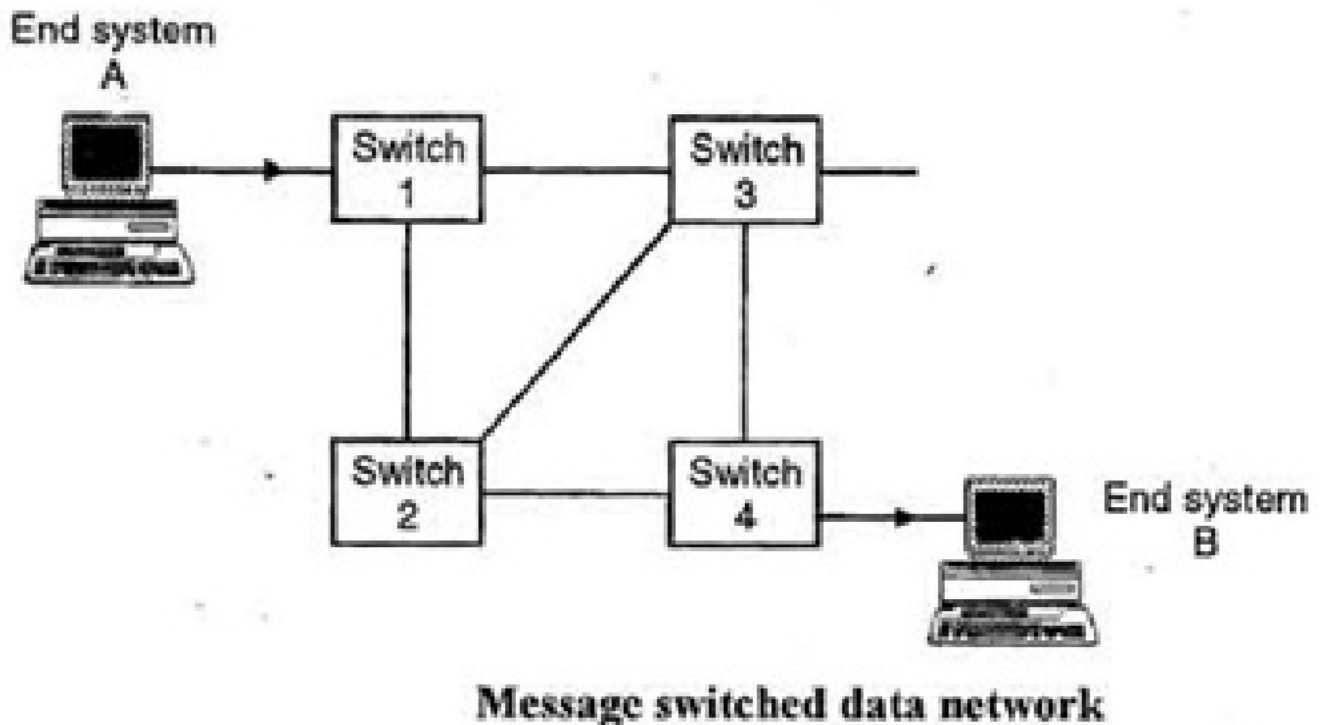
Section: Information System Operations, Maintenance and Support The word INCORRECTLY is the keyword used in the question. You need to find out a statement which is not valid about circuit switching.

For your exam you should know below information about WAN message transmission technique:

Message Switching

Message switching is a network switching technique in which data is routed in its entirety from the source node to the destination node, one hop at a time. During message routing, every intermediate switch in the network stores the whole message. If the entire network's resources are engaged or the network becomes blocked, the message-switched network stores and delays the message until ample resources become available for effective transmission of the message.

Message Switching

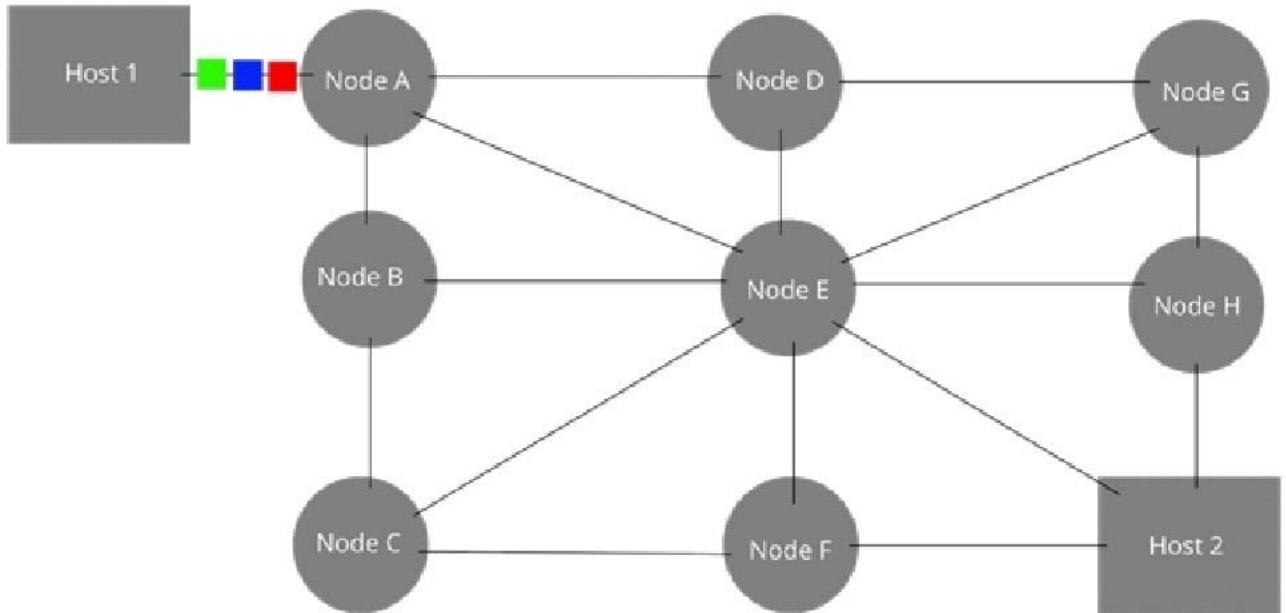


Packet Switching

Refers to protocols in which messages are divided into packets before they are sent. Each packet is then transmitted individually and can even follow different routes to its destination. Once all the packets forming a message arrive at the destination, they are recompiled into the original message.

Packet Switching

The original message is **Green**, **Blue**, **Red**.



Circuit Switching

Circuit switching is a methodology of implementing a telecommunications network in which two network nodes establish a dedicated communications channel (circuit) through the network before the nodes may communicate.

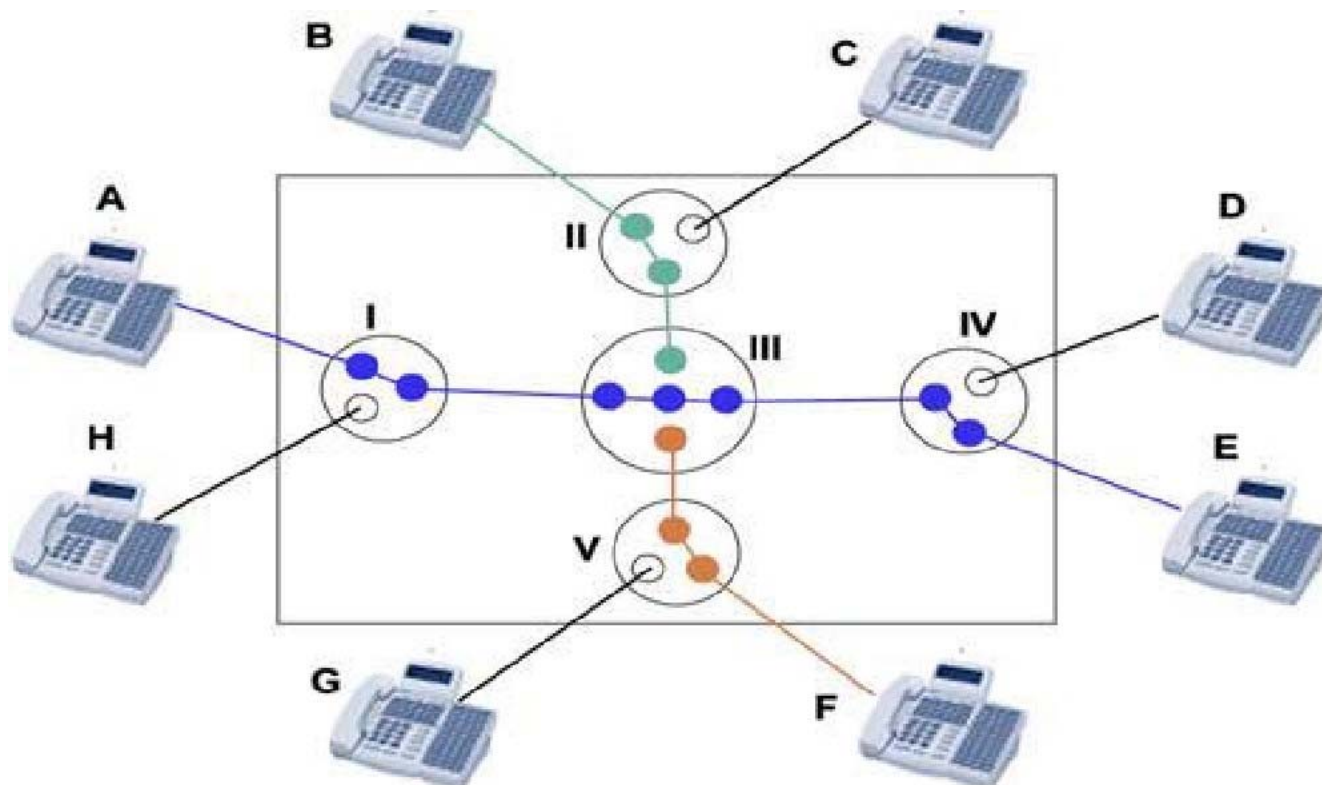
The circuit guarantees the full bandwidth of the channel and remains connected for the duration of the session. The circuit functions as if the nodes were physically connected similar to an electrical circuit.

The defining example of a circuit-switched network is the early analog telephone network. When a call is made from one telephone to another, switches within the telephone exchanges create a continuous wire circuit between the two telephones, for as long as the call lasts.

In circuit switching, the bit delay is constant during a connection, as opposed to packet switching, where packet queues may cause varying and potentially indefinitely long packet transfer delays. No circuit can be

degraded by competing users because it is protected from use by other callers until the circuit is released and a new connection is set up. Even if no actual communication is taking place, the channel remains reserved and protected from competing users.

Circuit Switching



See a table below comparing Circuit Switched versus Packet Switched networks:
Difference between Circuit and packet switching

	Circuit Switching	Packet Switching
Dedicated “copper” path	Yes	No
Bandwidth available	Fixed	Dynamic
Potentially wasted bandwidth	Yes	No
Store-and-forward-transmission	No	Yes
Each packet follows the same route	Yes	No
Call setup	Required	Not required
When can congestion occur	At setup time	On every packet
Charging	Per minute	Per packet

Virtual circuit

In telecommunications and computer networks, a virtual circuit (VC), synonymous with virtual connection and virtual channel, is a connection oriented communication service that is delivered by means of packet mode communication.

After a connection or virtual circuit is established between two nodes or application processes, a bit stream or byte stream may be delivered between the nodes; a virtual circuit protocol allows higher level protocols to avoid dealing with the division of data into segments, packets, or frames.

Virtual circuit communication resembles circuit switching, since both are connection oriented, meaning that in both cases data is delivered in correct order, and signaling overhead is required during a connection establishment phase. However, circuit switching provides constant bit rate and latency, while these may vary in a virtual circuit service due to factors such as:

varying packet queue lengths in the network nodes,
varying bit rate generated by the application,
varying load from other users sharing the same network resources by means of statistical multiplexing, etc.

The following were incorrect answers:

The other options presented correctly describes about circuit switching.

QUESTION 436

Which of the following statement INCORRECTLY describes packet switching technique?

- A. Packet uses many different dynamic paths to get the same destination
- B. Traffic is usually burst in nature
- C. Fixed delays to reach each packet to destination
- D. Usually carries data-oriented data

Correct Answer: C

Explanation

Explanation/Reference:

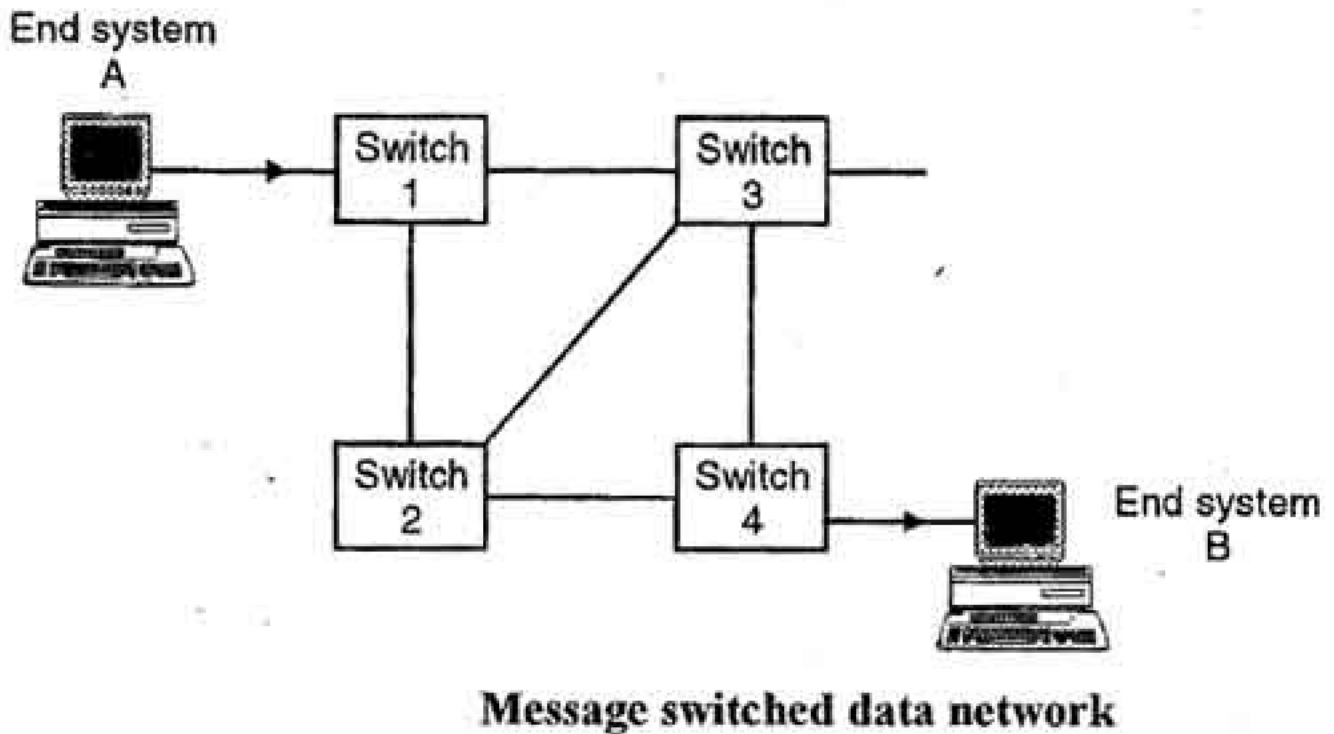
Section: Information System Operations, Maintenance and Support The word INCORRECTLY is the keyword used in the question. You need to find out a statement which is not valid about packet switching. As in the network switching, packet traverse different path, there will be always variable delay for each packet to reach to destination.

For your exam you should know below information about WAN message transmission technique:

Message Switching

Message switching is a network switching technique in which data is routed in its entirety from the source node to the destination node, one hop at a time. During message routing, every intermediate switch in the network stores the whole message. If the entire network's resources are engaged or the network becomes blocked, the message-switched network stores and delays the message until ample resources become available for effective transmission of the message.

Message Switching

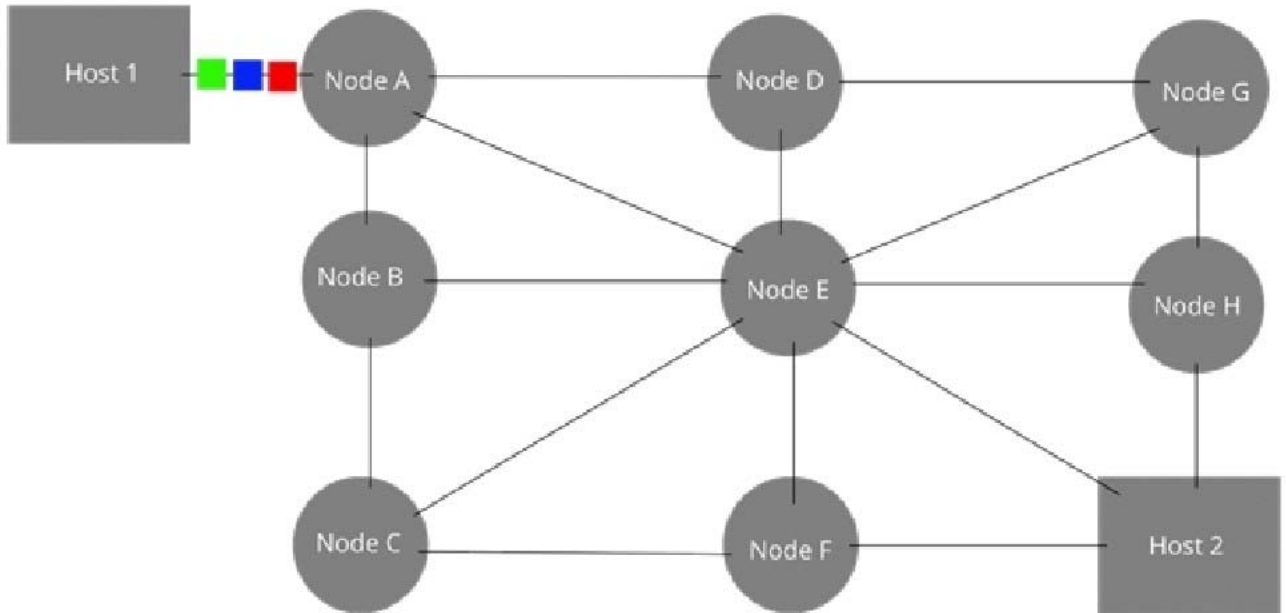


Packet Switching

Refers to protocols in which messages are divided into packets before they are sent. Each packet is then transmitted individually and can even follow different routes to its destination. Once all the packets forming a message arrive at the destination, they are recompiled into the original message.

Packet Switching

The original message is **Green**, **Blue**, **Red**.



Circuit Switching

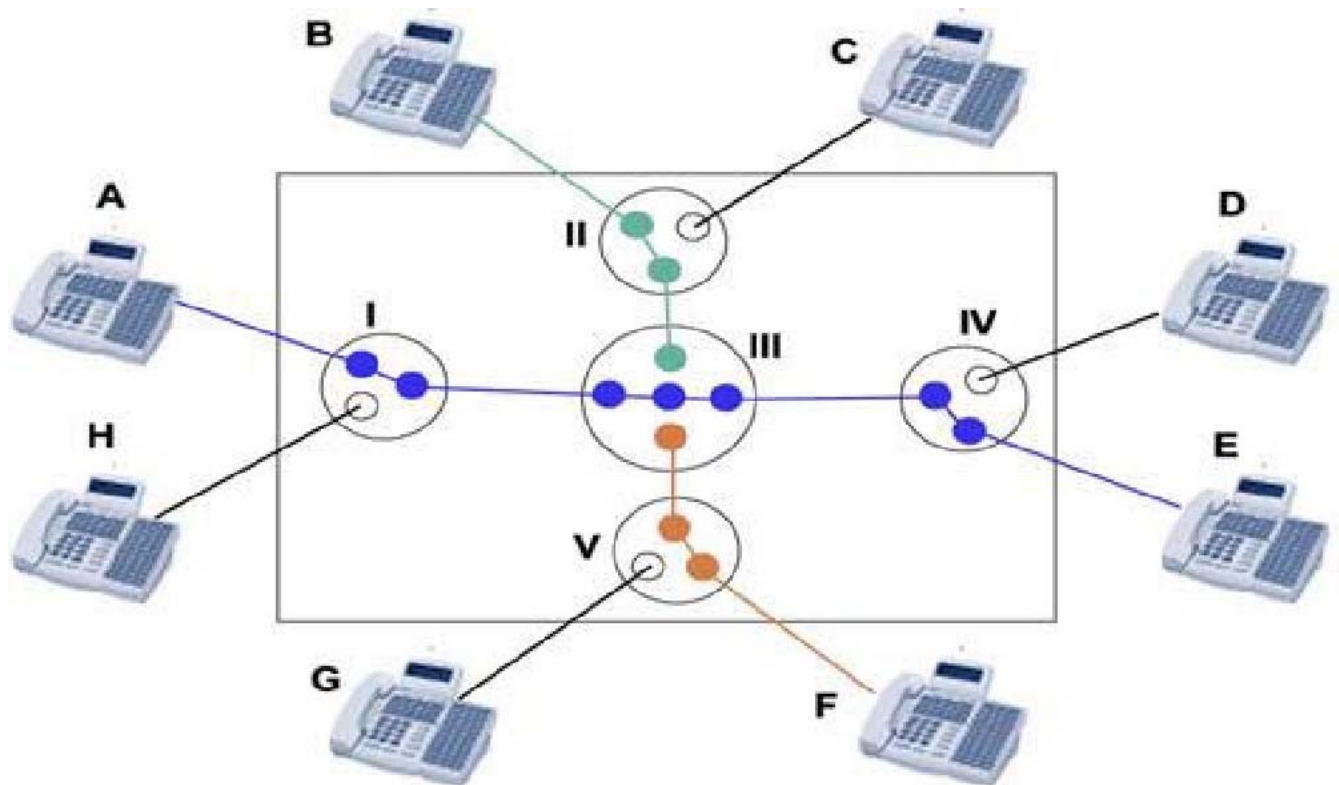
Circuit switching is a methodology of implementing a telecommunications network in which two network nodes establish a dedicated communications channel (circuit) through the network before the nodes may communicate.

The circuit guarantees the full bandwidth of the channel and remains connected for the duration of the session. The circuit functions as if the nodes were physically connected similar to an electrical circuit. The defining example of a circuit-switched network is the early analog telephone network. When a call is made from one telephone to another, switches within the telephone exchanges create a continuous wire circuit between the two telephones, for as long as the call lasts.

In circuit switching, the bit delay is constant during a connection, as opposed to packet switching, where packet queues may cause varying and potentially indefinitely long packet transfer delays. No circuit can be

degraded by competing users because it is protected from use by other callers until the circuit is released and a new connection is set up. Even if no actual communication is taking place, the channel remains reserved and protected from competing users.

Circuit Switching



See a table below comparing Circuit Switched versus Packet Switched networks:
Difference between Circuit and packet switching

	Circuit Switching	Packet Switching
Dedicated “copper” path	Yes	No
Bandwidth available	Fixed	Dynamic
Potentially wasted bandwidth	Yes	No
Store-and-forward-transmission	No	Yes
Each packet follows the same route	Yes	No
Call setup	Required	Not required
When can congestion occur	At setup time	On every packet
Charging	Per minute	Per packet

Virtual circuit

In telecommunications and computer networks, a virtual circuit (VC), synonymous with virtual connection and virtual channel, is a connection oriented communication service that is delivered by means of packet mode communication.

After a connection or virtual circuit is established between two nodes or application processes, a bit stream or byte stream may be delivered between the nodes; a virtual circuit protocol allows higher level protocols to avoid dealing with the division of data into segments, packets, or frames.

Virtual circuit communication resembles circuit switching, since both are connection oriented, meaning that in both cases data is delivered in correct order, and signaling overhead is required during a connection establishment phase. However, circuit switching provides constant bit rate and latency, while these may vary in a virtual circuit service due to factors such as:

varying packet queue lengths in the network nodes,
varying bit rate generated by the application,
varying load from other users sharing the same network resources by means of statistical multiplexing, etc.

The following were incorrect answers:

The other options presented correctly describes about packet switching.

CISA review manual 2014 Page number 265

QUESTION 437

Which of the following protocol uses serial interface for communication between two computers in WAN technology?

- A. Point-to-point protocol
- B. X.25
- C. Frame Relay
- D. ISDN

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support PPP (Point-to-Point Protocol) is a protocol for communication between two computers using a serial interface, typically a personal computer using a MODEM connected by phone line to a server.

For your exam you should know below information about WAN Technologies:

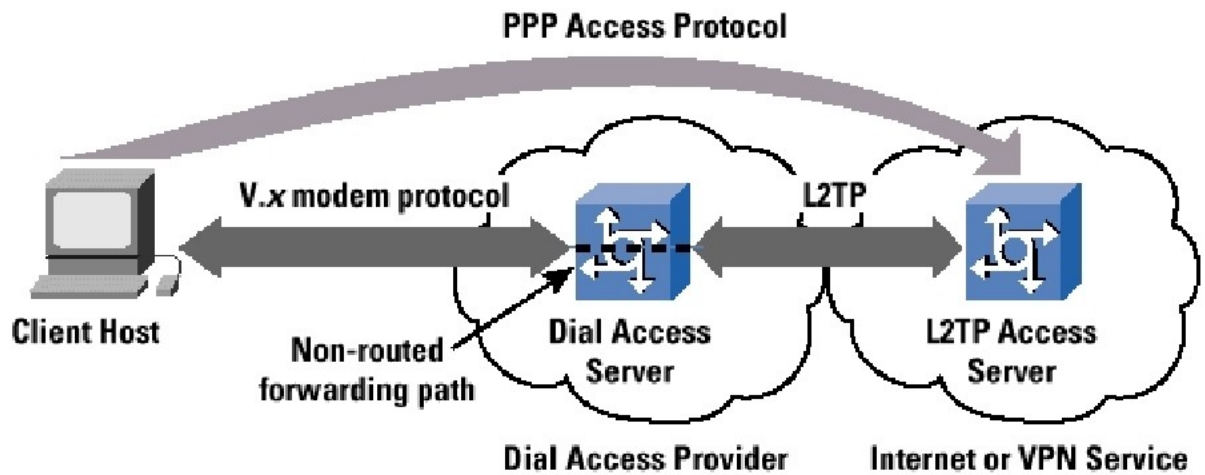
Point-to-point protocol

PPP (Point-to-Point Protocol) is a protocol for communication between two computers using a serial interface, typically a personal computer connected by phone line to a server. For example, your Internet server provider may provide you with a PPP connection so that the provider's server can respond to your requests, pass them on to the Internet, and forward your requested Internet responses back to you. PPP uses the Internet protocol (IP) (and is designed to handle others). It is sometimes considered a member of the TCP/IP suite of protocols. Relative to the Open Systems Interconnection (OSI) reference model, PPP provides layer 2 (data-link layer) service. Essentially, it packages your computer's TCP/IP packets and forwards them to the server where they can actually be put on the Internet.

PPP is a full-duplex protocol that can be used on various physical media, including twisted pair or fiber optic lines or satellite transmission. It uses a variation of High Speed Data Link Control (HDLC) for packet encapsulation.

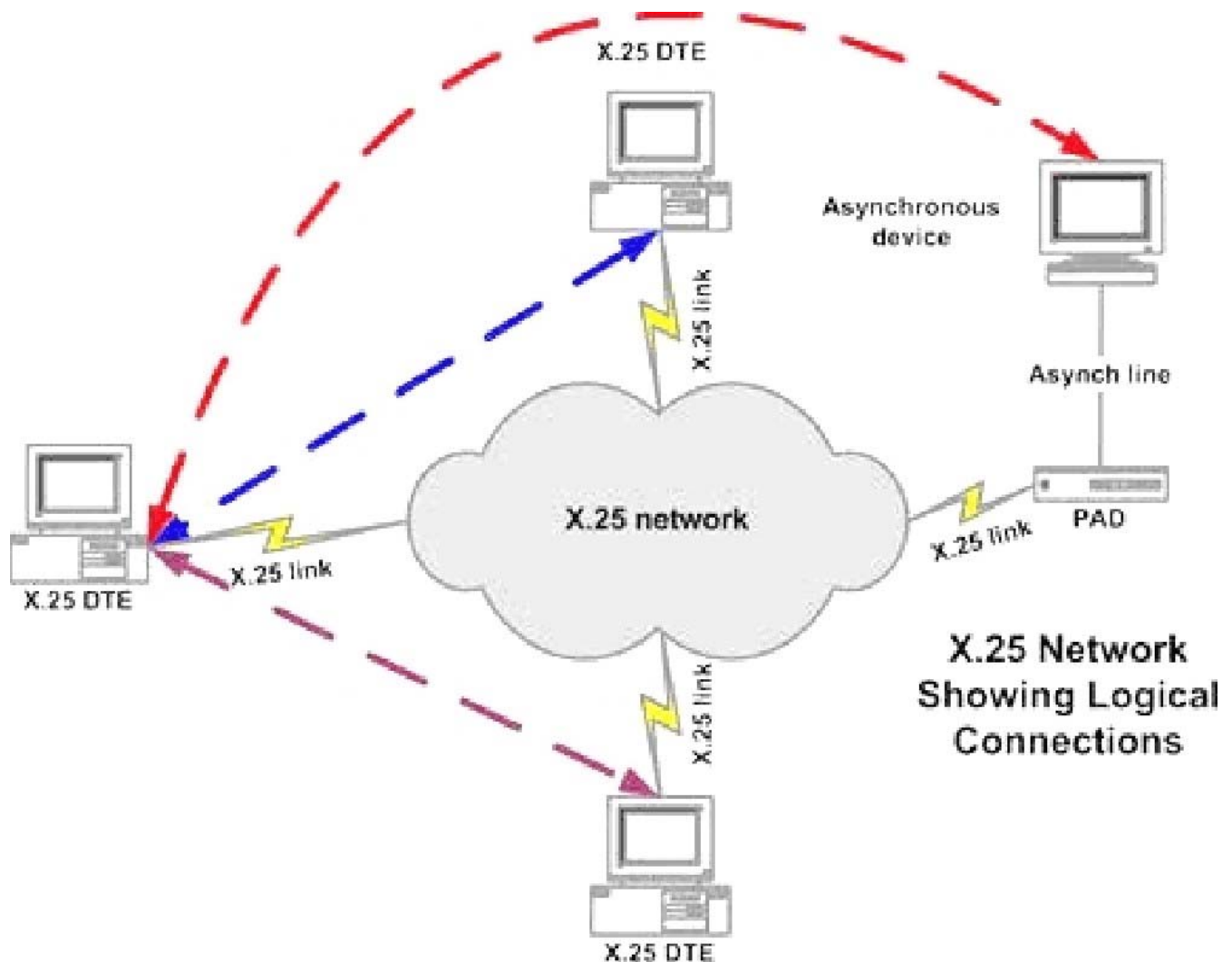
PPP is usually preferred over the earlier de facto standard Serial Line Internet Protocol (SLIP) because it can handle synchronous as well as asynchronous communication. PPP can share a line with other users and it has error detection that SLIP lacks. Where a choice is possible, PPP is preferred.

Point-to-point protocol



X.25

X.25 is an ITU-T standard protocol suite for packet switched wide area network (WAN) communication. X.25 is a packet switching technology which uses carrier switch to provide connectivity for many different networks. Subscribers are charged based on amount of bandwidth they use. Data are divided into 128 bytes and encapsulated in High Level Data Link Control (HDLC). X.25 works at network and data link layer of an OSI model.



X.25

Frame Relay

Works on a packet switching
 Operates at data link layer of an OSI model
 Companies that pay more to ensure that a higher level of bandwidth will always be available, pay a committed information rate or CIR

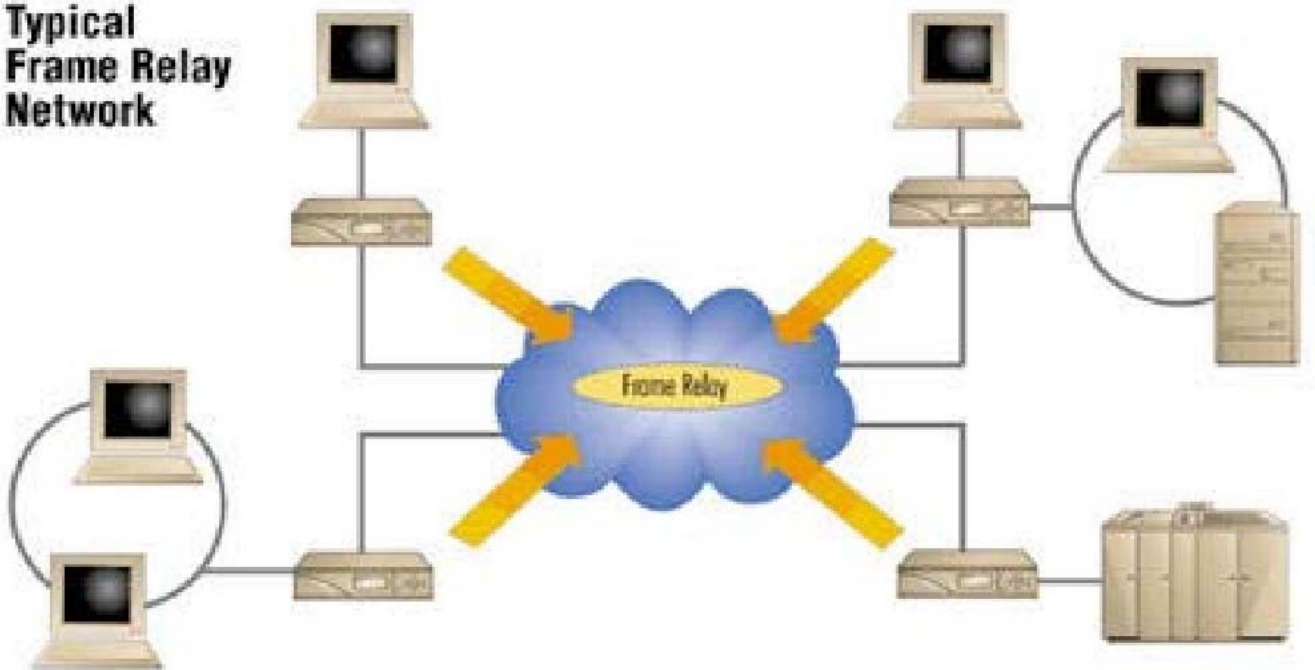
Two main types of equipment's are used in Frame Relay

1. Data Terminal Equipment (DTE) - Usually a customer owned device that provides a connectivity between company's own network and the frame relay's network.

2. Data Circuit Terminal Equipment (DCE) - Service provider device that does the actual data transmission and switching in the frame relay cloud.

The Frame relay cloud is the collection of DCE that provides that provides switching and data communication functionality. Frame relay is any to any service.

Typical Frame Relay Network



Frame Relay
Integrated Service Digital Network

Enables data, voice and other types of traffic to travel over a medium in a digital manner previously used only for analog voice transmission.
Same copper telephone wire is used.

Provide digital point-to-point circuit switching medium.

ISDN



Asynchronous Transfer Mode (ATM)

Uses Cell switching method

High speed network technology used for LAN, MAN and WAN

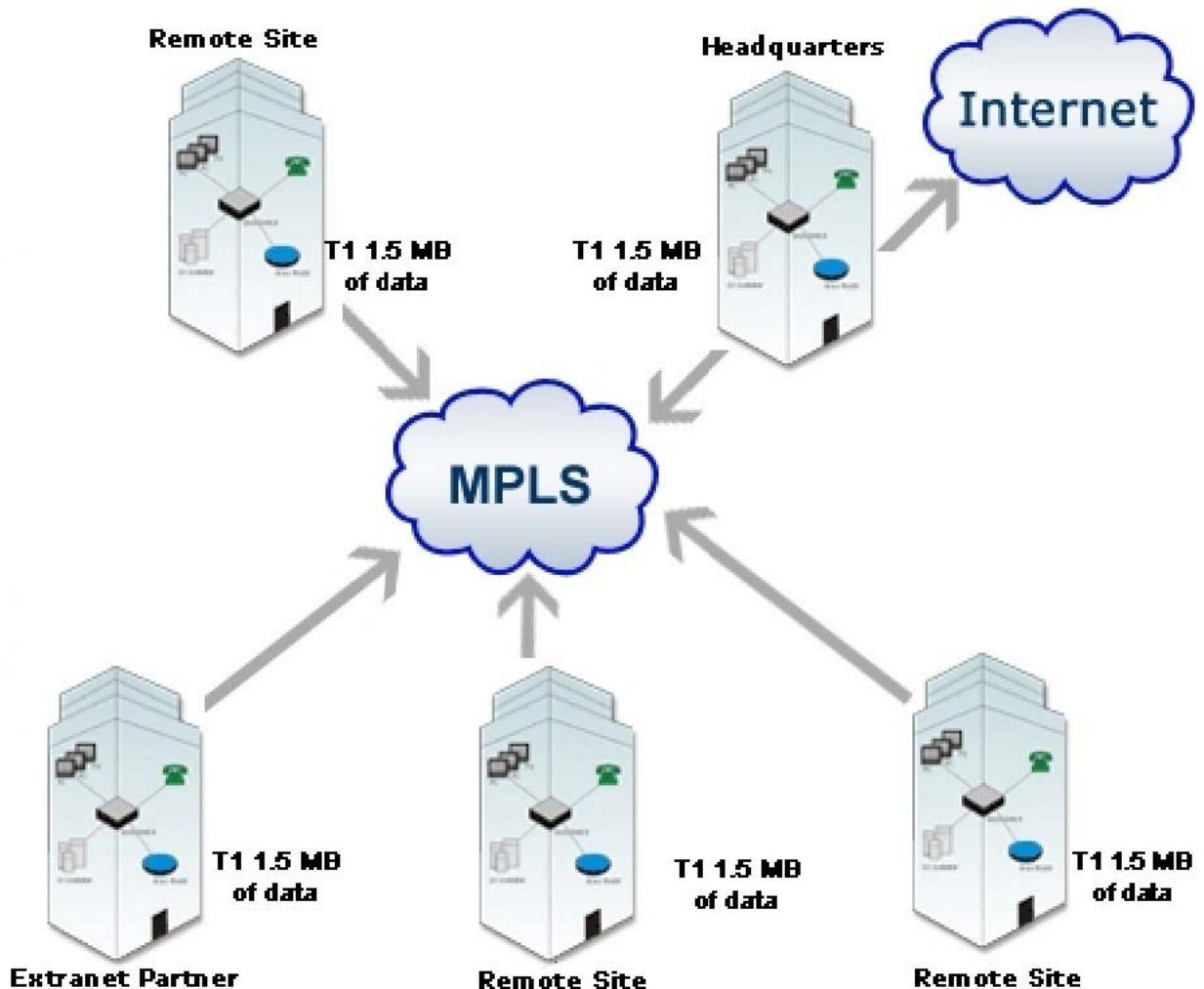
Like a frame relay it is connection oriented technology which creates and uses fixed channel Data are segmented into fixed size cell of 53 bytes
Some companies have replaced FDDI back-end with ATM

Asynchronous Transfer Mode

Multiprotocol Label Switching (MPLS)

Multiprotocol Label Switching (MPLS) is a standards-approved technology for speeding up network traffic flow and making it easier to manage. MPLS involves setting up a specific path for a given sequence of packets, identified by a label put in each packet, thus saving the time needed for a router to look up the address to the next node to forward the packet to. MPLS is called multiprotocol because it works with the Internet Protocol (IP), Asynchronous Transport Mode (ATM), and frame relay network protocols. With reference to the standard model for a network (the Open Systems Interconnection, or OSI model), MPLS allows most packets to be forwarded at the Layer 2 (switching) level rather than at the Layer 3 (routing) level. In addition to moving traffic faster overall, MPLS makes it easy to manage a network for quality of service (QoS). For these reasons, the technique is expected to be readily adopted as networks begin to carry more and different mixtures of traffic.

MPLS



The following answers are incorrect:

X.25 - X.25 is an ITU-T standard protocol suite for packet switched wide area network (WAN) communication. X.25 is a packet switching technology which uses carrier switch to provide connectivity for many different networks.

Frame Relay - The Frame relay cloud is the collection of DCE that provides that provides switching and data communication functionality. Frame relay is any to any service.

ISDN -Enables data, voice and other types of traffic to travel over a medium in a digital manner previously used only for analog voice transmission. Same copper telephone wire is used. Provide digital point-to-point circuit switching medium.
CISA review manual 2014 page number 266

QUESTION 438

Which of the following is a ITU-T standard protocol suite for packet switched wide area network communication?

- A. Point-to-point protocol
- B. X.25
- C. Frame Relay
- D. ISDN

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support X.25 is an ITU-T standard protocol suite for packet switched wide area network (WAN) communication. X.25 is a packet switching technology which uses carrier switch to provide connectivity for many different networks.

For your exam you should know below information about WAN Technologies:

The following answers are incorrect:

Point-to-point protocol - PPP (Point-to-Point Protocol) is a protocol for communication between two computers using a serial interface, typically a personal computer connected by phone line to a server. Frame Relay - The Frame relay cloud is the collection of DCE that provides that provides switching and data communication functionality. Frame relay is any to any service.

ISDN -Enables data, voice and other types of traffic to travel over a medium in a digital manner previously used only for analog voice transmission. Same copper telephone wire is used. Provide digital point-to-point circuit switching medium.
CISA review manual 2014 page number 266

QUESTION 439

Which of the following device in Frame Relay WAN technique is generally customer owned device that provides a connectivity between company's own network and the frame relays network?

- A. DTE
- B. DCE
- C. DME
- D. DLE

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Data Terminal Equipment (DTE) - Usually a customer owned device that provides connectivity between company's own network and the frame relay's network.

For your exam you should know below information about WAN Technologies:

Point-to-point protocol

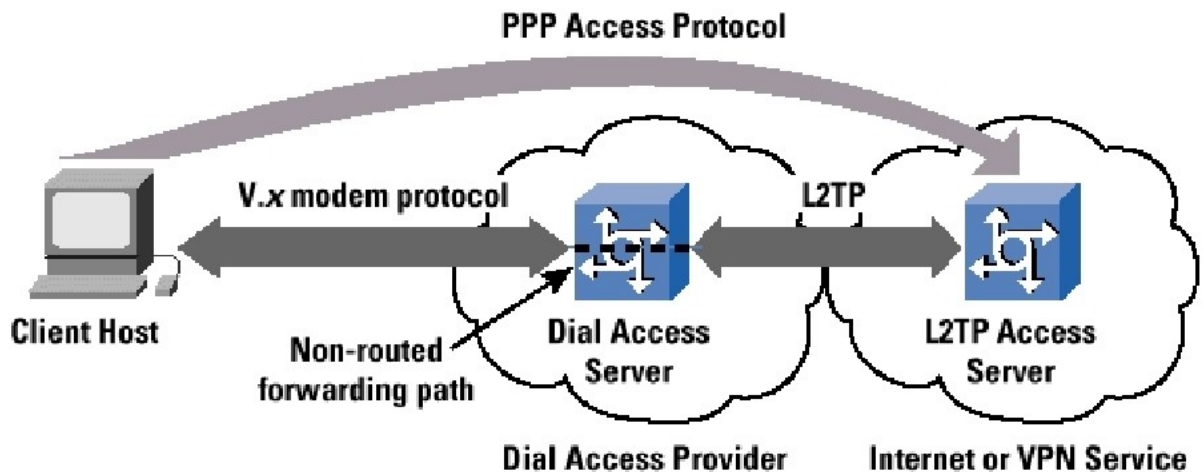
PPP (Point-to-Point Protocol) is a protocol for communication between two computers using a serial interface, typically a personal computer connected by phone line to a server. For example, your Internet server provider may provide you with a PPP connection so that the provider's server can respond to your requests, pass them on to the Internet, and forward your requested Internet responses back to you.

PPP uses the Internet protocol (IP) (and is designed to handle other protocol as well). It is sometimes considered a member of the TCP/IP suite of protocols. Relative to the Open Systems Interconnection (OSI) reference model, PPP provides layer 2 (data-link layer) service. Essentially, it packages your computer's TCP/IP packets and forwards them to the server where they can actually be put on the Internet.

PPP is a full-duplex protocol that can be used on various physical media, including twisted pair or fiber optic lines or satellite transmission. It uses a variation of High Speed Data Link Control (HDLC) for packet encapsulation.

PPP is usually preferred over the earlier de facto standard Serial Line Internet Protocol (SLIP) because it can handle synchronous as well as asynchronous communication. PPP can share a line with other users and it has error detection that SLIP lacks. Where a choice is possible, PPP is preferred.

Point-to-point protocol



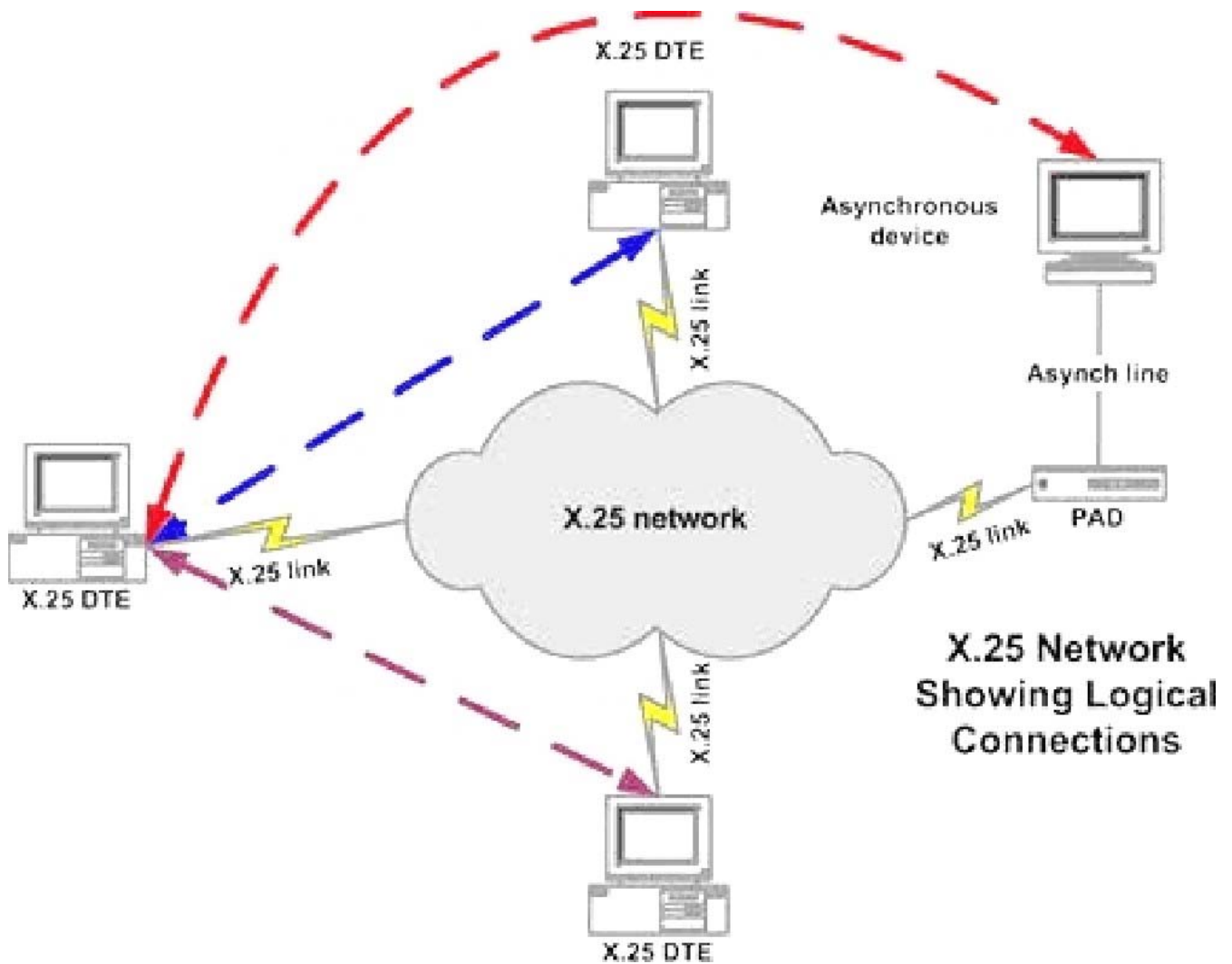
X.25

X.25 is an ITU-T standard protocol suite for packet switched wide area network (WAN) communication. X.25 is a packet switching technology which uses carrier switch to provide connectivity for many different networks.

Subscribers are charged based on amount of bandwidth they use. Data are divided into 128 bytes and encapsulated in High Level Data Link Control (HDLC).

X.25 works at network and data link layer of an OSI model.

X.25



Frame Relay

Works as packet switching

Operates at data link layer of an OSI model

Companies that pay more to ensure that a higher level of bandwidth will always be available, pay a committed information rate or CIR

Two main types of equipment's are used in Frame Relay

1. Data Terminal Equipment (DTE) - Usually a customer owned device that provides connectivity between company's own network and the frame relay's network.
2. Data Circuit Terminal Equipment (DCE) - Service provider device that does the actual data transmission and switching in the frame relay cloud.

The Frame relay cloud is the collection of DCE that provides that provides switching and data communication functionality. Frame relay is any to any service.

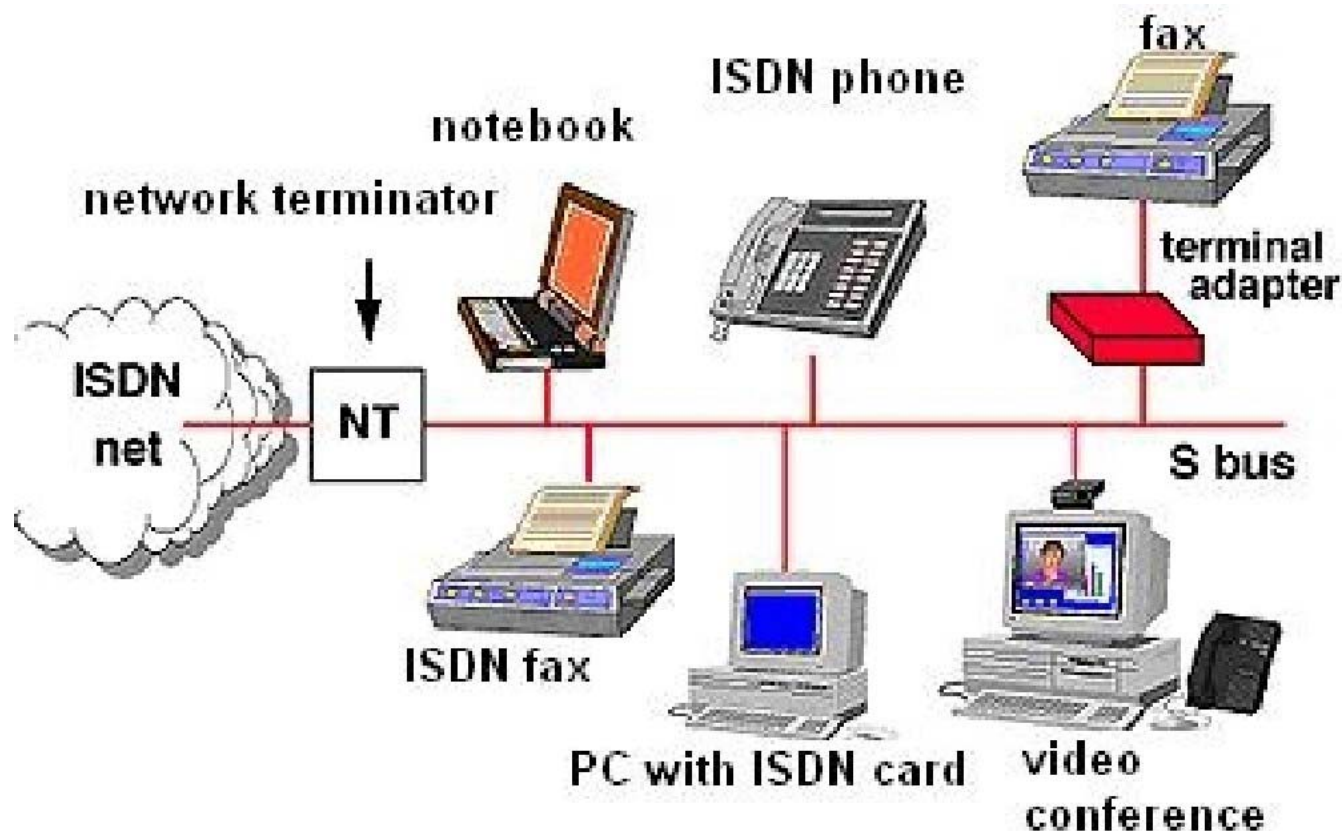
Frame Relay



Integrated Service Digital Network (ISDN)

Enables data, voice and other types of traffic to travel over a medium in a digital manner previously used only for analog voice transmission. Runs on top of the Plain Old Telephone System (POTS). The same copper telephone wire is used. Provide digital point-to-point circuit switching medium.

ISDN



Asynchronous Transfer Mode (ATM)

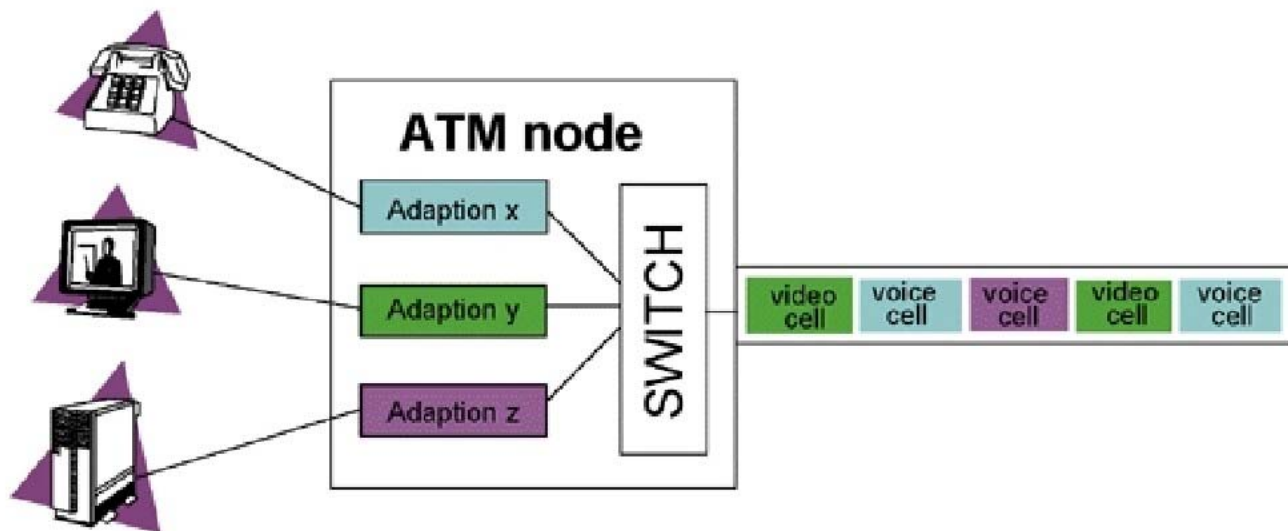
Uses Cell switching method

High speed network technology used for LAN, MAN and WAN

Like frame relay it is connection oriented technology which creates and uses fixed channel Data are segmented into fixed size cell of 53 bytes

Some companies have replaces FDDI back-end with ATM

Asynchronous Transfer Mode



Services	Adaptation layer	ATM layer	Physical Layer
----------	------------------	-----------	----------------

Multiprotocol Label Switching (MPLS)

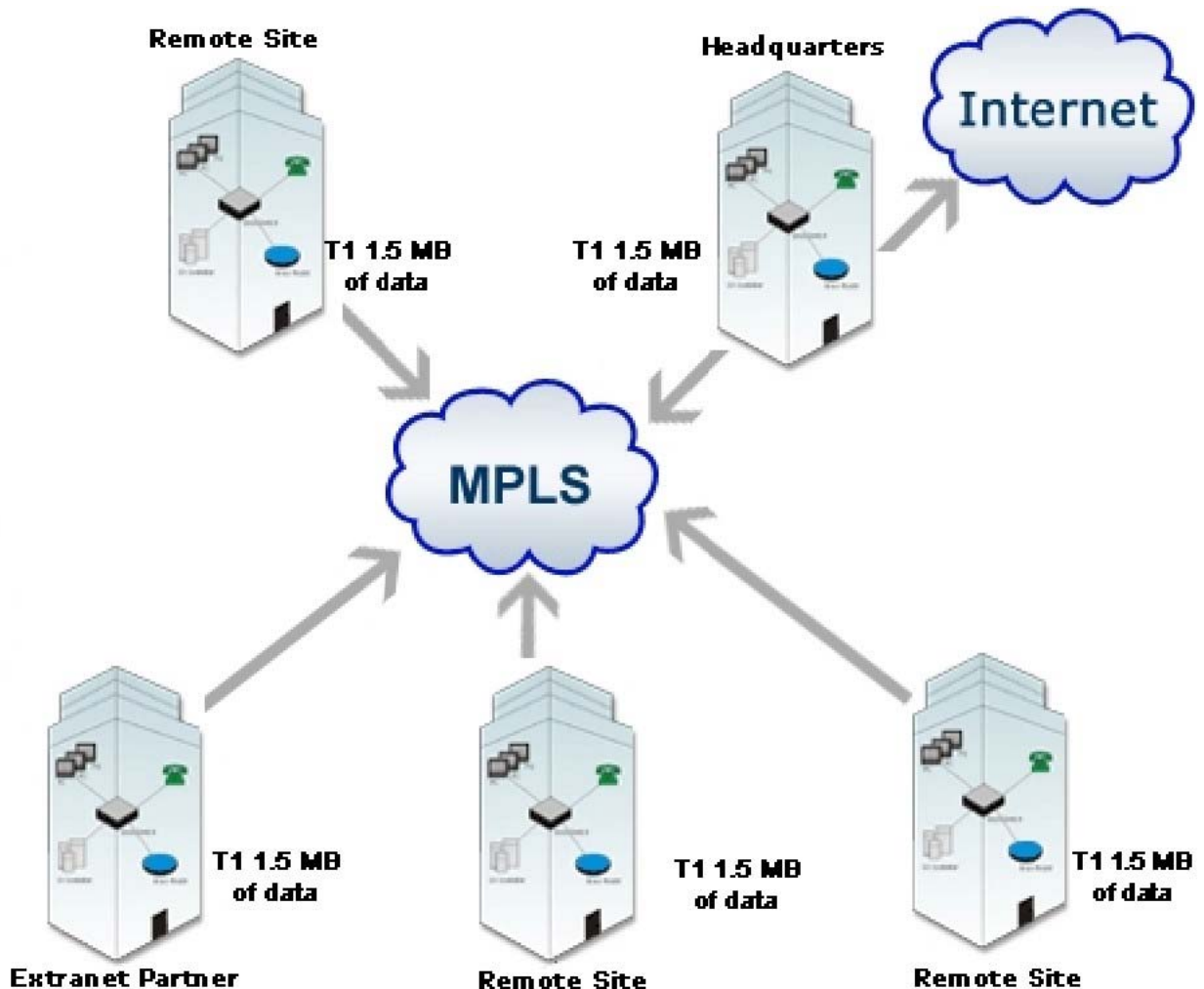
Multiprotocol Label Switching (MPLS) is a standard-approved technology for speeding up network traffic flow and making things easier to manage. MPLS involves setting up a specific path for a given sequence of packets, identified by a label put in each packet, thus saving the time needed for a router to look up the address to the next node to forward the packet to.

MPLS is called multiprotocol because it works with the Internet Protocol (IP), Asynchronous Transport Mode (ATM), and frame relay network protocols.

In reference to the Open Systems Interconnection, or OSI model, MPLS allows most packets to be forwarded at Layer 2 (switching) level rather than at the Layer 3 (routing) level.

In addition to moving traffic faster overall, MPLS makes it easy to manage a network for quality of service (QoS). For these reasons, the technique is expected to be readily adopted as networks begin to carry more and different mixtures of traffic.

MPLS



The following answers are incorrect:

DCE - Data Circuit Terminal Equipment (DCE) is a service provider device that does the actual data transmission and switching in the frame relay cloud.

DME Not a valid frame relay technique

DLE Not a valid frame relay technique

CISA review manual 2014 page number 266

QUESTION 440

Which of the following device in Frame Relay WAN technique is a service provider device that does the actual data transmission and switching in the frame relay cloud?

- A. DTE
- B. DCE
- C. DME
- D. DLE

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Data Circuit Terminal Equipment (DCE) is a service provider device that does the actual data transmission and switching in the frame relay cloud.

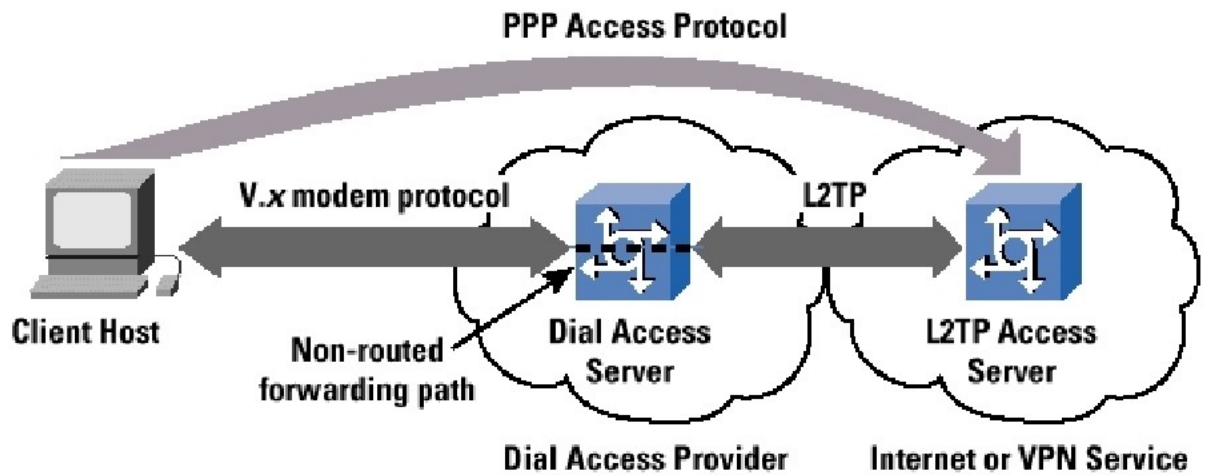
For your exam you should know below information about WAN Technologies:

Point-to-point protocol

PPP (Point-to-Point Protocol) is a protocol for communication between two computers using a serial interface, typically a personal computer connected by phone line to a server. For example, your Internet server provider may provide you with a PPP connection so that the provider's server can respond to your requests, pass them on to the Internet, and forward your requested Internet responses back to you. PPP uses the Internet protocol (IP) (and is designed to handle others). It is sometimes considered a member of the TCP/IP suite of protocols. Relative to the Open Systems Interconnection (OSI) reference model, PPP provides layer 2 (data-link layer) service. Essentially, it packages your computer's TCP/IP packets and forwards them to the server where they can actually be put on the Internet.

PPP is a full-duplex protocol that can be used on various physical media, including twisted pair or fiber optic lines or satellite transmission. It uses a variation of High Speed Data Link Control (HDLC) for packet encapsulation.

PPP is usually preferred over the earlier de facto standard Serial Line Internet Protocol (SLIP) because it can handle synchronous as well as asynchronous communication. PPP can share a line with other users and it has error detection that SLIP lacks. Where a choice is possible, PPP is preferred.

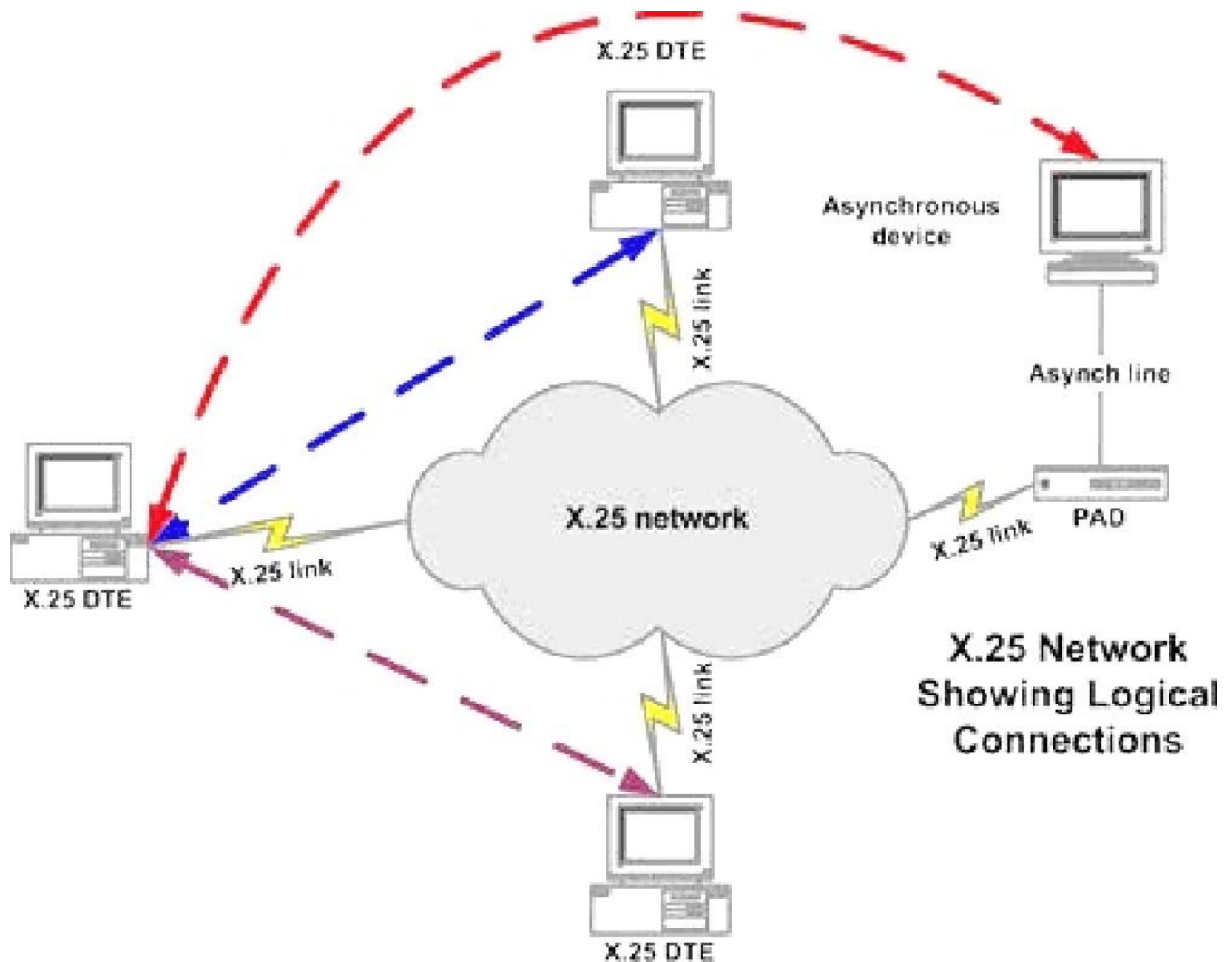


Point-to-point protocol

X.25

X.25 is an ITU-T standard protocol suite for packet switched wide area network (WAN) communication. X.25 is a packet switching technology which uses carrier switch to provide connectivity for many different networks. Subscribers are charged based on amount of bandwidth they use. Data are divided into 128 bytes and encapsulated in High Level Data Link Control (HDLC). X.25 works at network and data link layer of an OSI model.

X.25



Frame Relay

Works on a packet switching

Operates at data link layer of an OSI model

Companies that pay more to ensure that a higher level of bandwidth will always be available, pay a committed information rate or CIR

Two main types of equipments are used in Frame Relay

1. Data Terminal Equipment (DTE) - Usually a customer owned device that provides a connectivity between company's own network and the frame relay's network.

2. Data Circuit Terminal Equipment (DCE) - Service provider device that does the actual data transmission and switching in the frame relay cloud.

The Frame relay cloud is the collection of DCE that provides that provides switching and data communication functionality. Frame relay is any to any service.

Frame Relay

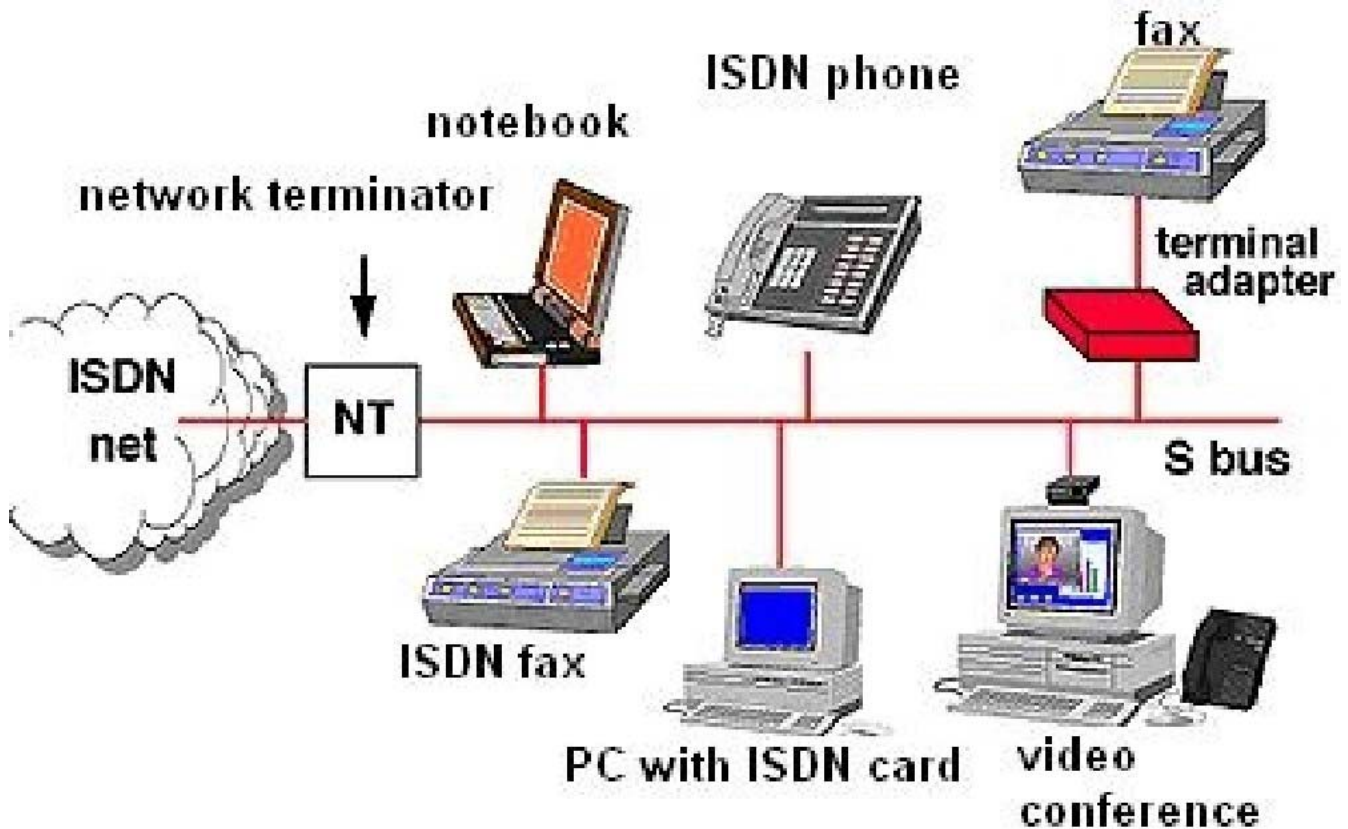
Integrated Service Digital Network

Enables data, voice and other types of traffic to travel over a medium in a digital manner previously used only for analog voice transmission.

Same copper telephone wire is used.

Provide digital point-to-point circuit switching medium

ISDN



Asynchronous Transfer Mode (ATM)

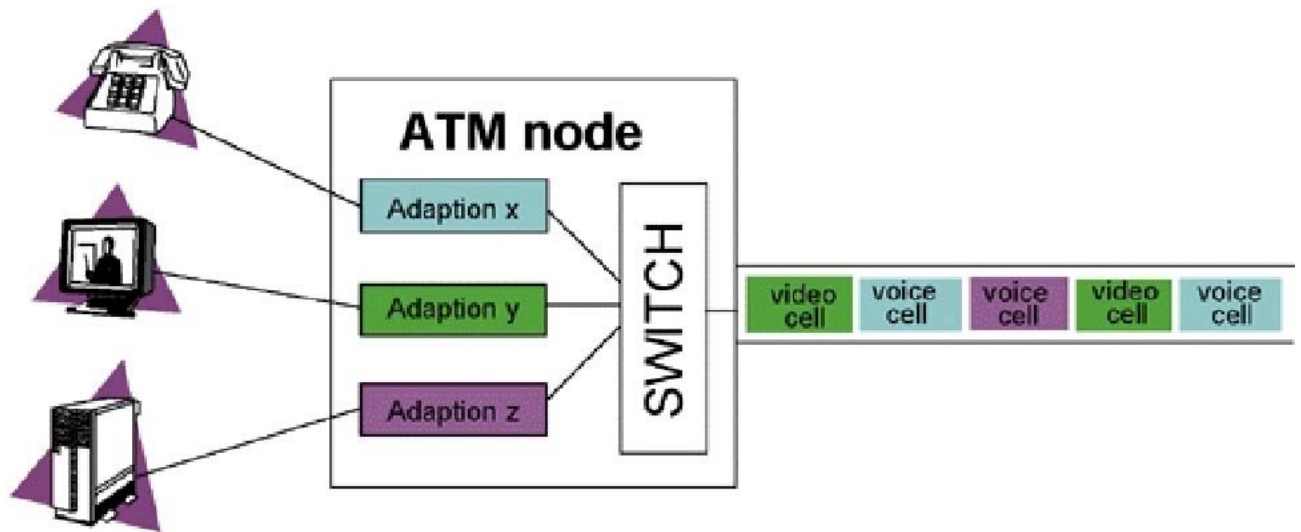
Uses Cell switching method

High speed network technology used for LAN, MAN and WAN

Like a frame relay it is connection oriented technology which creates and uses fixed channel Data are segmented into fixed size cell of 53 bytes

Some companies have replaces FDDI back-end with ATM

Asynchronous Transfer Mode

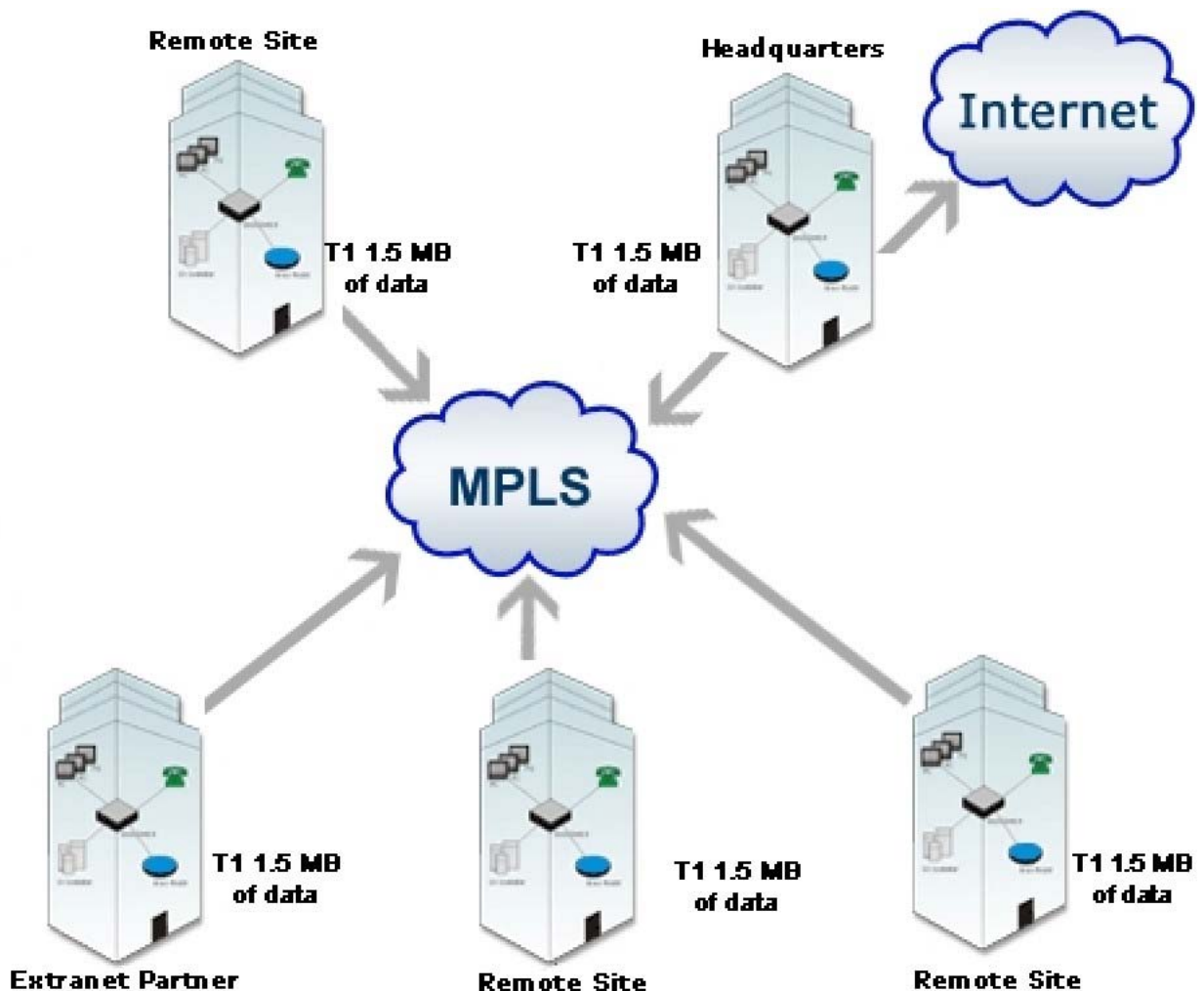


Services	Adaptation layer	ATM layer	Physical Layer
----------	------------------	-----------	----------------

Multiprotocol Label Switching (MPLS)

Multiprotocol Label Switching (MPLS) is a standards-approved technology for speeding up network traffic flow and making it easier to manage. MPLS involves setting up a specific path for a given sequence of packets, identified by a label put in each packet, thus saving the time needed for a router to look up the address to the next node to forward the packet to. MPLS is called multiprotocol because it works with the Internet Protocol (IP), Asynchronous Transport Mode (ATM), and frame relay network protocols. With reference to the standard model for a network (the Open Systems Interconnection, or OSI model), MPLS allows most packets to be forwarded at the Layer 2 (switching) level rather than at the Layer 3 (routing) level. In addition to moving traffic faster overall, MPLS makes it easy to manage a network for quality of service (QoS). For these reasons, the technique is expected to be readily adopted as networks begin to carry more and different mixtures of traffic.

MPLS



The following answers are incorrect:

DTE - Data Terminal Equipment (DTE) is usually a customer owned device that provides a connectivity between company's own network and the frame relay's network.

DME Not a valid frame relay technique

DLE Not a valid frame relay technique

CISA review manual 2014 page number 266

QUESTION 441

Which of the following statement INCORRECTLY describes Asynchronous Transfer Mode (ATM) technique?

- A. ATM uses cell switching method
- B. ATM is high speed network technology used for LAN, MAN and WAN
- C. ATM works at session layer of an OSI model
- D. Data are segmented into fixed size cell of 53 bytes

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The keyword INCORRECTLY is used within the question. You need to find out a statement which was incorrectly describe Asynchronous Transfer Mode. ATM operates at data link layer of an OSI model

For your exam you should know below information about WAN Technologies:

Point-to-point protocol

PPP (Point-to-Point Protocol) is a protocol for communication between two computers using a serial interface, typically a personal computer connected by phone line to a server. For example, your Internet server provider may provide you with a PPP connection so that the provider's server can respond to your requests, pass them on to the Internet, and forward your requested Internet responses back to you. PPP uses the Internet protocol (IP) (and is designed to handle others). It is sometimes considered a member of the TCP/IP suite of protocols. Relative to the Open Systems Interconnection (OSI) reference model, PPP provides layer 2 (data-link layer) service. Essentially, it packages your computer's TCP/IP packets and forwards them to the server where they can actually be put on the Internet.

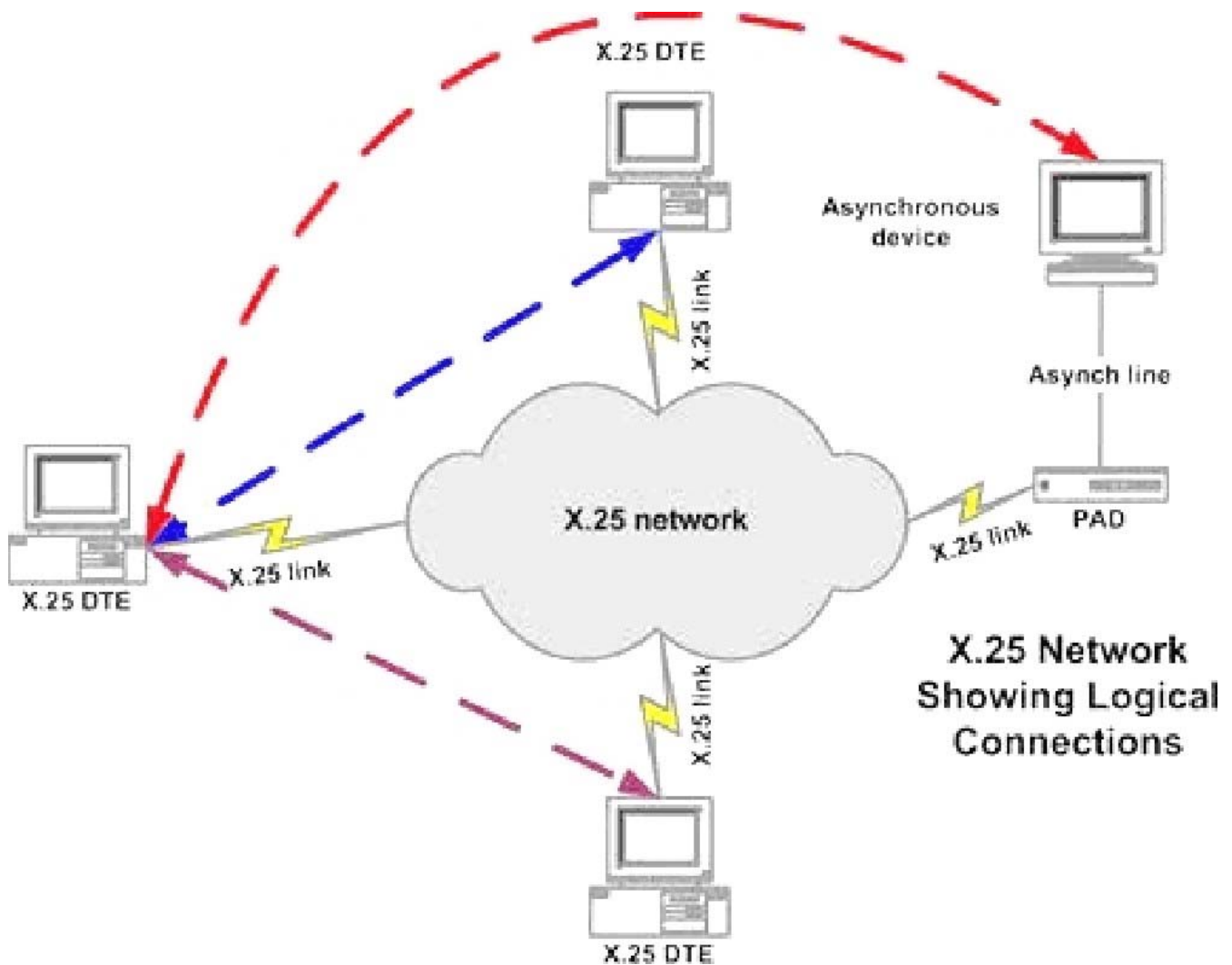
PPP is a full-duplex protocol that can be used on various physical media, including twisted pair or fiber optic lines or satellite transmission. It uses a variation of High Speed Data Link Control (HDLC) for packet encapsulation.

PPP is usually preferred over the earlier de facto standard Serial Line Internet Protocol (SLIP) because it can handle synchronous as well as asynchronous communication. PPP can share a line with other users and it has error detection that SLIP lacks. Where a choice is possible, PPP is preferred.

Point-to-point protocol

X.25

X.25 is an ITU-T standard protocol suite for packet switched wide area network (WAN) communication. X.25 is a packet switching technology which uses carrier switch to provide connectivity for many different networks. Subscribers are charged based on amount of bandwidth they use. Data are divided into 128 bytes and encapsulated in High Level Data Link Control (HDLC). X.25 works at network and data link layer of an OSI model.



X.25

Frame Relay

Works on a packet switching
Operates at data link layer of an OSI model
Companies that pay more to ensure that a higher level of bandwidth will always be available, pay a committed information rate or CIR

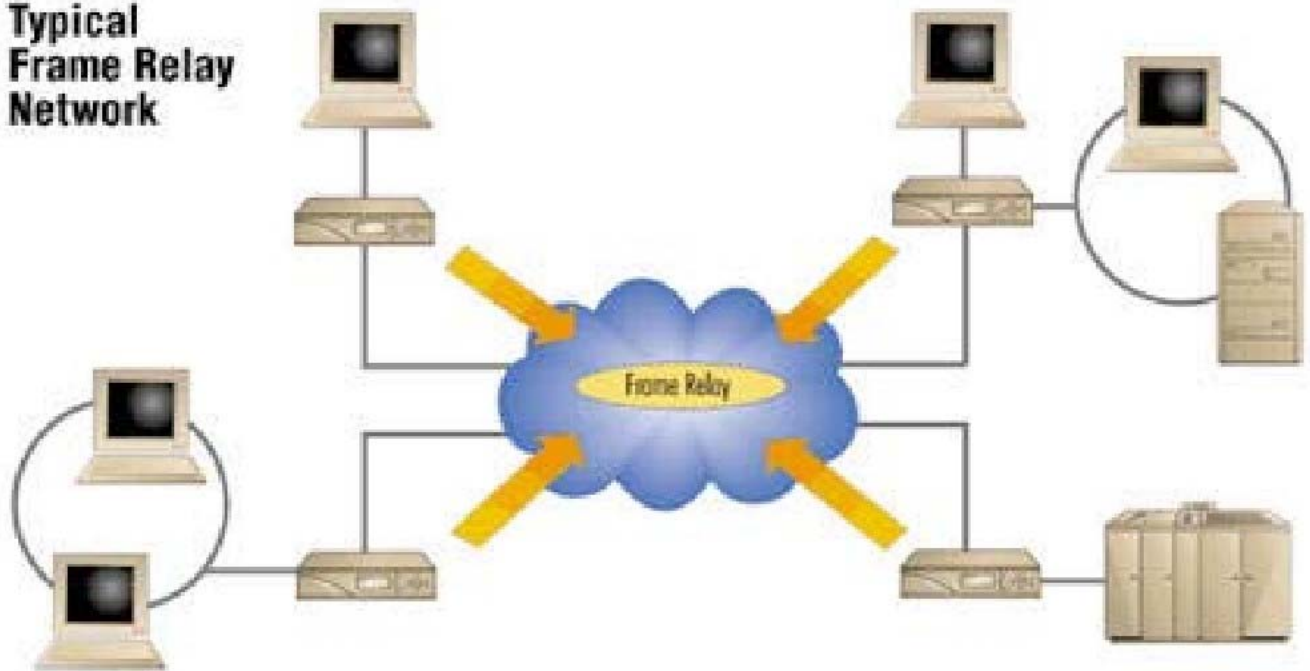
Two main types of equipment's are used in Frame Relay

1. Data Terminal Equipment (DTE) - Usually a customer owned device that provides a connectivity between company's own network and the frame relay's network.

2. Data Circuit Terminal Equipment (DCE) - Service provider device that does the actual data transmission and switching in the frame relay cloud.

The Frame relay cloud is the collection of DCE that provides that provides switching and data communication functionality. Frame relay is any to any service.

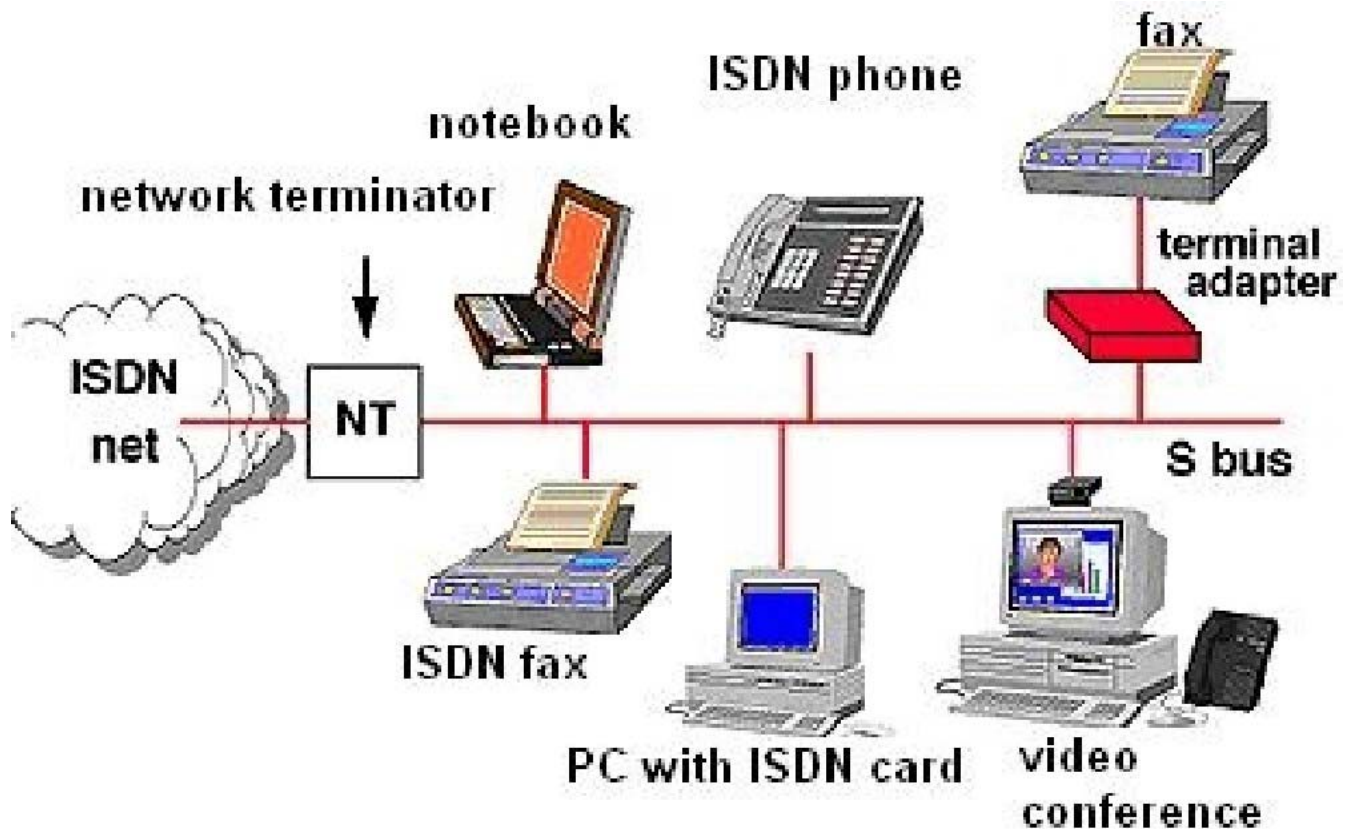
Typical Frame Relay Network



Frame Relay

Integrated Service Digital Network

Enables data, voice and other types of traffic to travel over a medium in a digital manner previously used only for analog voice transmission.
Same copper telephone wire is used.
Provide digital point-to-point circuit switching medium.

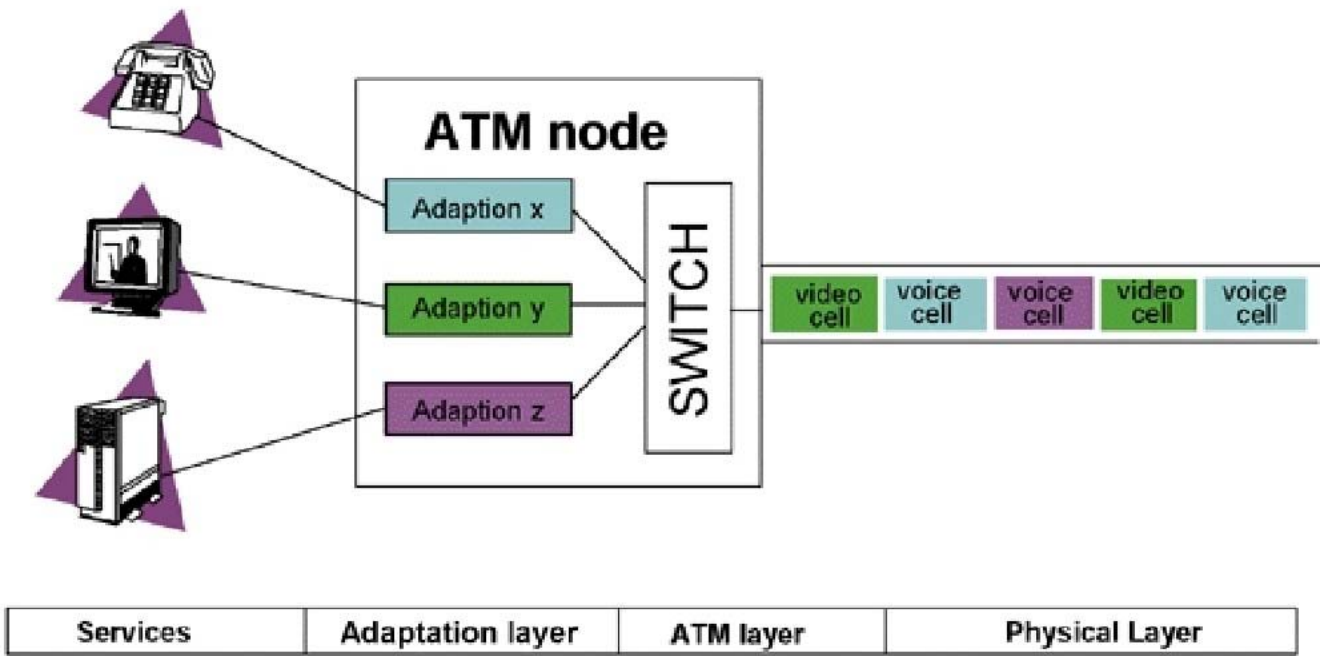


ISDN

Asynchronous Transfer Mode (ATM)

Uses Cell switching method
High speed network technology used for LAN, MAN and WAN
Like a frame relay it is connection oriented technology which creates and uses fixed channel Data are segmented into fixed size cell of 53 bytes

Some companies have replaces FDDI back-end with ATM

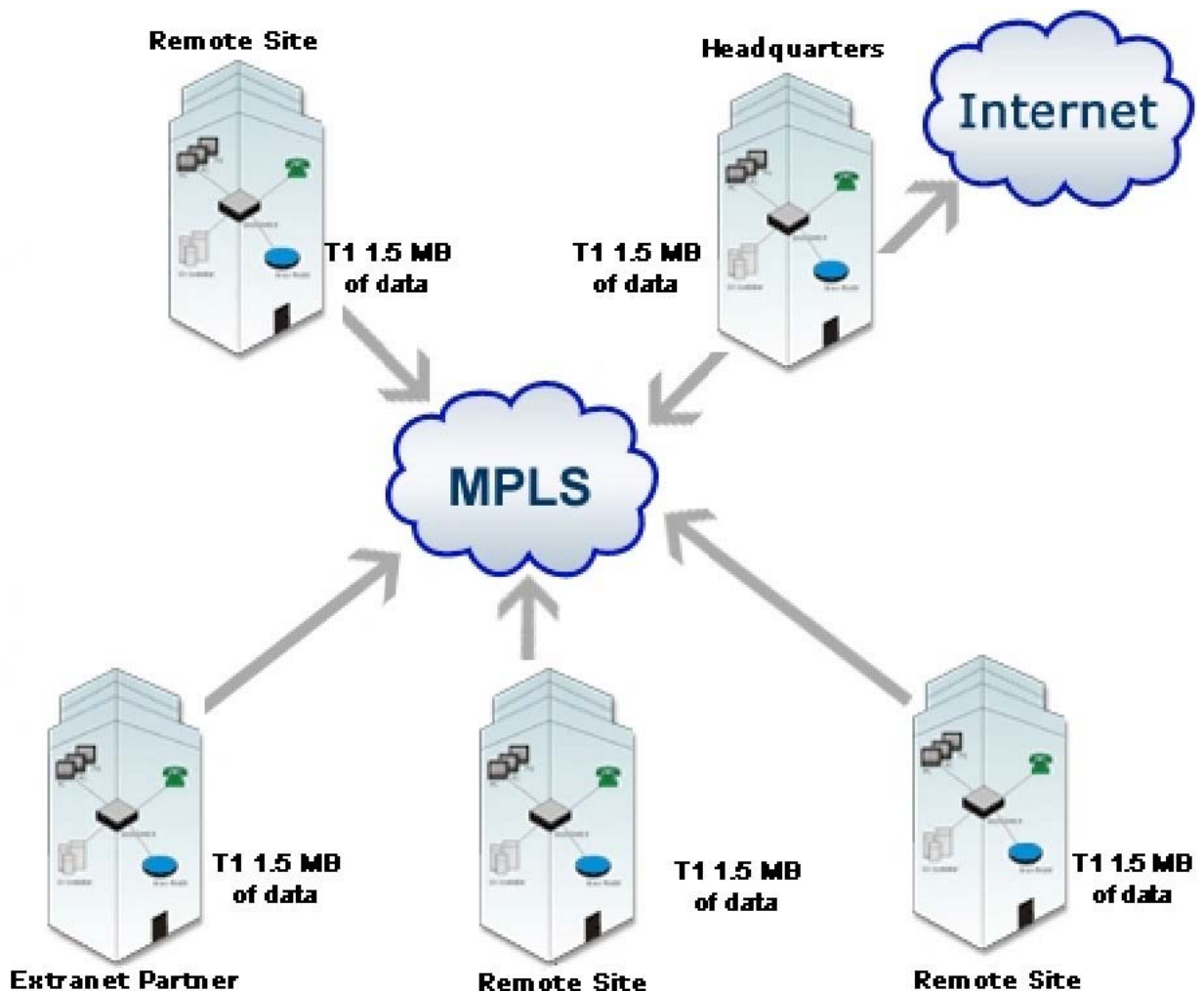


Asynchronous Transfer Mode

Multiprotocol Label Switching (MPLS)

Multiprotocol Label Switching (MPLS) is a standards-approved technology for speeding up network traffic flow and making it easier to manage. MPLS involves setting up a specific path for a given sequence of packets, identified by a label put in each packet, thus saving the time needed for a router to look up the address to the next node to forward the packet to. MPLS is called multiprotocol because it works with the Internet Protocol (IP), Asynchronous Transport Mode (ATM), and frame relay network protocols. With reference to the standard model for a network (the Open Systems Interconnection, or OSI model), MPLS allows most packets to be forwarded at the Layer 2 (switching) level rather than at the Layer 3 (routing) level. In addition to moving traffic faster overall, MPLS makes it easy to manage a network for quality of service (QoS). For these reasons, the technique is expected to be readily adopted as networks begin to carry more and different mixtures of traffic.

MPLS



The following answers are incorrect:
The other options presented correctly describes Asynchronous Transfer Mode.
CISA review manual 2014 page number 266

QUESTION 442

Which of the following technique is used for speeding up network traffic flow and making it easier to manage?

- A. Point-to-point protocol
- B. X.25
- C. MPLS
- D. ISDN

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Multiprotocol Label Switching (MPLS) is a standards-approved technology for speeding up network traffic flow and making it easier to manage. MPLS involves setting up a specific path for a given sequence of packets, identified by a label put in each packet, thus saving the time needed for a router to look up the address to the next node to forward the packet to. MPLS is called multiprotocol because it works with the Internet Protocol (IP), Asynchronous Transport Mode (ATM), and frame relay network protocols. With reference to the standard model for a network (the Open Systems Interconnection, or OSI model), MPLS allows most packets to be forwarded at the Layer 2 (switching) level rather than at the Layer 3 (routing) level. In addition to moving traffic faster overall, MPLS makes it easy to manage a network for quality of service (QoS). For these reasons, the technique is expected to be readily adopted as networks begin to carry more and different mixtures of traffic.

For your exam you should know below information about WAN Technologies:

Point-to-point protocol

PPP (Point-to-Point Protocol) is a protocol for communication between two computers using a serial interface, typically a personal computer connected by phone line to a server. For example, your Internet server provider may provide you with a PPP connection so that the provider's server can respond to your requests, pass them on to the Internet, and forward your requested Internet responses back to you. PPP uses the Internet protocol (IP) (and is designed to handle others). It is sometimes considered a member of the TCP/IP suite of protocols. Relative to the Open Systems Interconnection (OSI) reference model, PPP provides layer 2 (data-link layer) service. Essentially, it packages your computer's TCP/IP packets and forwards them to the server where they can actually be put on the Internet.

PPP is a full-duplex protocol that can be used on various physical media, including twisted pair or fiber optic lines or satellite transmission. It uses a variation of High Speed Data Link Control (HDLC) for packet

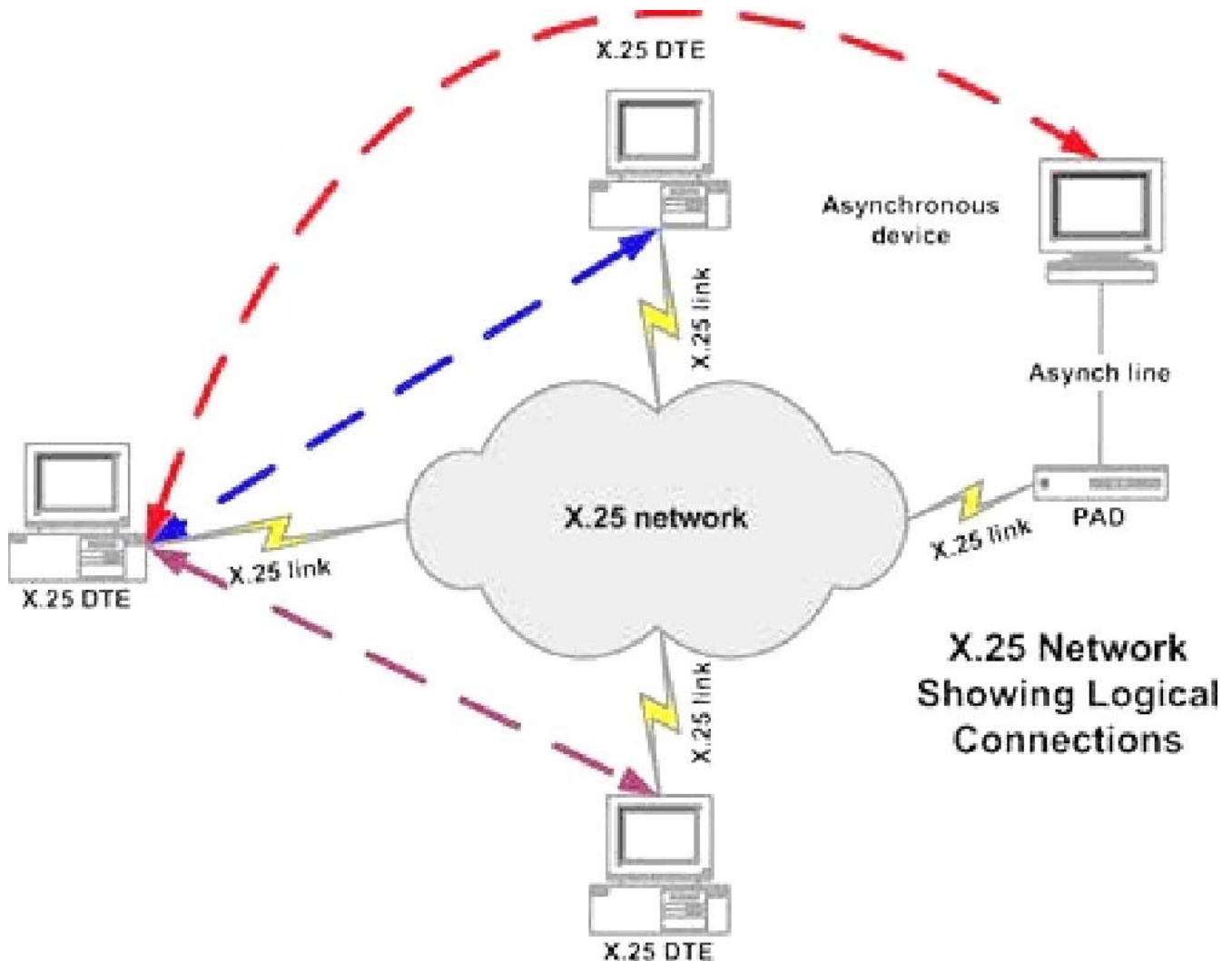
encapsulation.

PPP is usually preferred over the earlier de facto standard Serial Line Internet Protocol (SLIP) because it can handle synchronous as well as asynchronous communication. PPP can share a line with other users and it has error detection that SLIP lacks. Where a choice is possible, PPP is preferred.

Point-to-point protocol

X.25

X.25 is an ITU-T standard protocol suite for packet switched wide area network (WAN) communication. X.25 is a packet switching technology which uses carrier switch to provide connectivity for many different networks. Subscribers are charged based on amount of bandwidth they use. Data are divided into 128 bytes and encapsulated in High Level Data Link Control (HDLC). X.25 works at network and data link layer of an OSI model.



X.25

Frame Relay

Works on a packet switching

Operates at data link layer of an OSI model

Companies that pay more to ensure that a higher level of bandwidth will always be available, pay a committed information rate or CIR

Two main types of equipment's are used in Frame Relay

1. Data Terminal Equipment (DTE) - Usually a customer owned device that provides a connectivity between company's own network and the frame relay's network.

2. Data Circuit Terminal Equipment (DCE) - Service provider device that does the actual data transmission and switching in the frame relay cloud.

The Frame relay cloud is the collection of DCE that provides that provides switching and data communication functionality. Frame relay is any to any service.

Frame Relay

Integrated Service Digital Network

Enables data, voice and other types of traffic to travel over a medium in a digital manner previously used only for analog voice transmission.

Same copper telephone wire is used.

Provide digital point-to-point circuit switching medium.

ISDN

Asynchronous Transfer Mode (ATM)

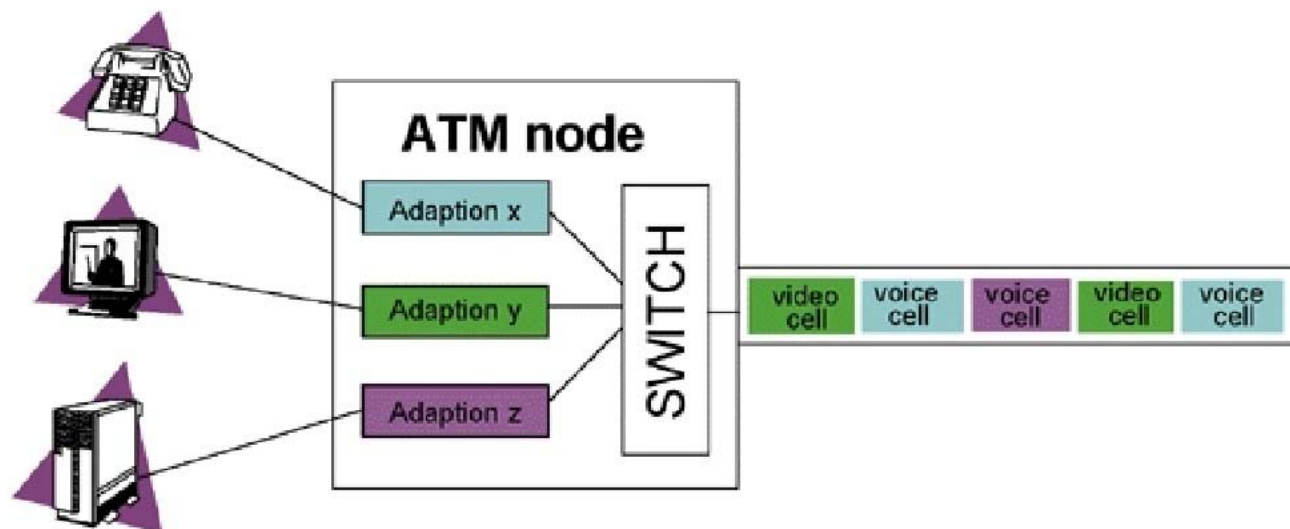
Uses Cell switching method

High speed network technology used for LAN, MAN and WAN

Like a frame relay it is connection oriented technology which creates and uses fixed channel Data are segmented into fixed size cell of 53 bytes

Some companies have replaces FDDI back-end with ATM

Asynchronous Transfer Mode

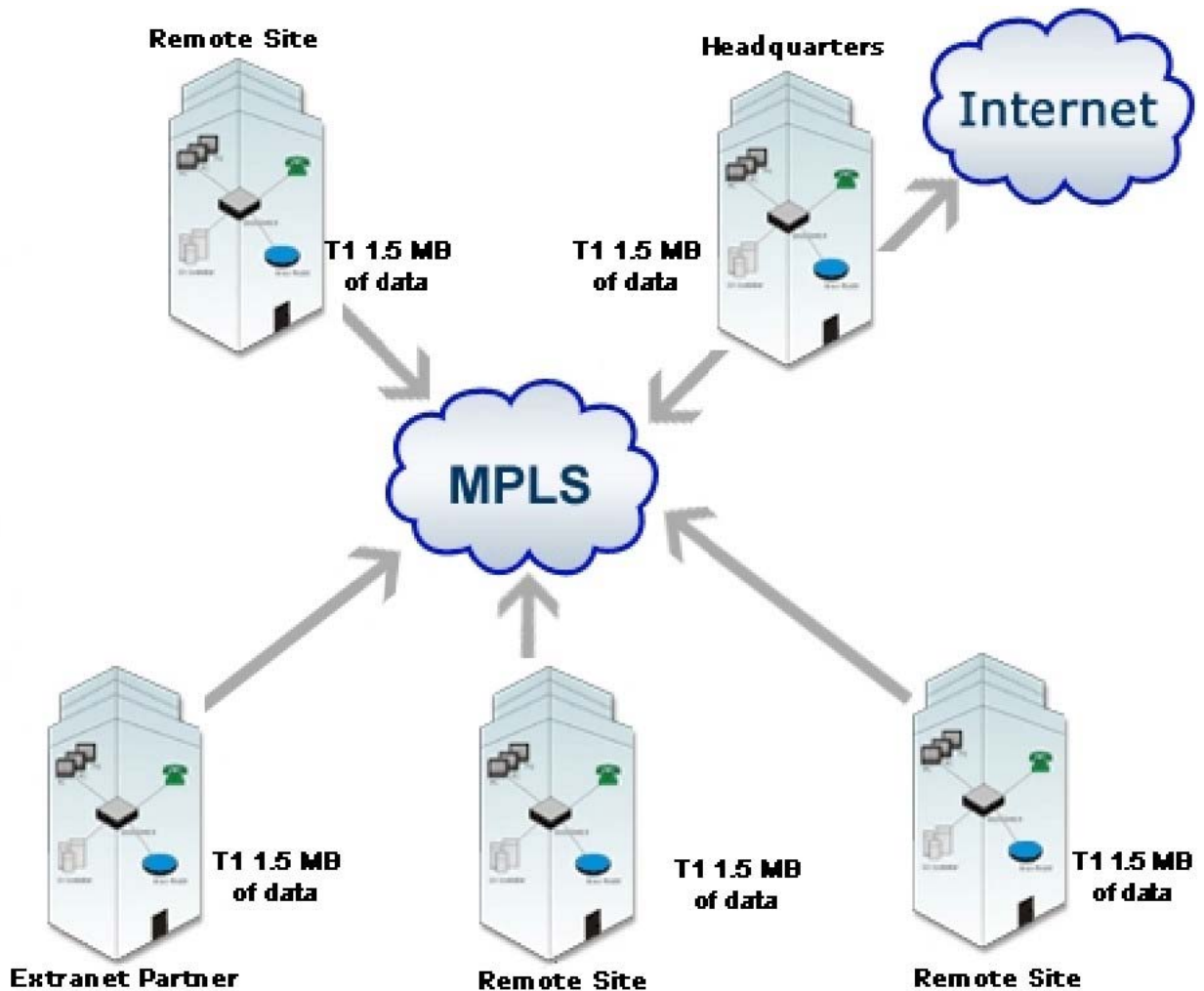


Services	Adaptation layer	ATM layer	Physical Layer
----------	------------------	-----------	----------------

Multiprotocol Label Switching (MPLS)

Multiprotocol Label Switching (MPLS) is a standards-approved technology for speeding up network traffic flow and making it easier to manage. MPLS involves setting up a specific path for a given sequence of packets, identified by a label put in each packet, thus saving the time needed for a router to look up the address to the next node to forward the packet to. MPLS is called multiprotocol because it works with the Internet Protocol (IP), Asynchronous Transport Mode (ATM), and frame relay network protocols. With reference to the standard model for a network (the Open Systems Interconnection, or OSI model), MPLS allows most packets to be forwarded at the Layer 2 (switching) level rather than at the Layer 3 (routing) level. In addition to moving traffic faster overall, MPLS makes it easy to manage a network for quality of service (QoS). For these reasons, the technique is expected to be readily adopted as networks begin to carry more and different mixtures of traffic.

MPLS



The following answers are incorrect:

X.25 - X.25 is an ITU-T standard protocol suite for packet switched wide area network (WAN) communication. X.25 is a packet switching technology which uses carrier switch to provide connectivity for many different networks.

Point-to-point protocol - PPP (Point-to-Point Protocol) is a protocol for communication between two computers using a serial interface, typically a personal computer connected by phone line to a server.

ISDN - Enables data, voice and other types of traffic to travel over a medium in a digital manner previously used only for analog voice transmission.
CISA review manual 2014 page number 266

QUESTION 443

An IS auditor should know information about different network transmission media. Which of the following transmission media is used for short distance transmission?

- A. Copper cable
- B. Fiber Optics
- C. Satellite Radio Link
- D. Satellite Radio Link

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data.

For your exam you should know below information about transmission media:

Copper Cable

Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data. Copper has been used in electric wiring since the invention of the electromagnet and the telegraph in the

1820s. The invention of the telephone in 1876 created further demand for copper wire as an electrical conductor.

Copper is the electrical conductor in many categories of electrical wiring. Copper wire is used in power generation, power transmission, power distribution, telecommunications, electronics circuitry, and countless types of electrical equipment. Copper and its alloys are also used to make electrical contacts. Electrical wiring in buildings is the most important market for the copper industry. Roughly half of all copper mined is used to manufacture electrical wire and cable conductors.

Copper Cable



Coaxial cable

Coaxial cable, or coax (pronounced 'ko.aks), is a type of cable that has an inner conductor surrounded by a tubular insulating layer, surrounded by a tubular conducting shield. Many coaxial cables also have an insulating outer sheath or jacket. The term coaxial comes from the inner conductor and the outer shield sharing a geometric axis. Coaxial cable was invented by English engineer and mathematician Oliver Heaviside, who patented the design in 1880. Coaxial cable differs from other shielded cable used for carrying lower-frequency signals, such as audio signals, in that the dimensions of the cable are controlled to give a precise, constant conductor spacing, which is needed for it to function efficiently as a radio frequency transmission line.

Coaxial cable is expensive and does not support many LAN's. It supports data and video.



Coaxial Cable

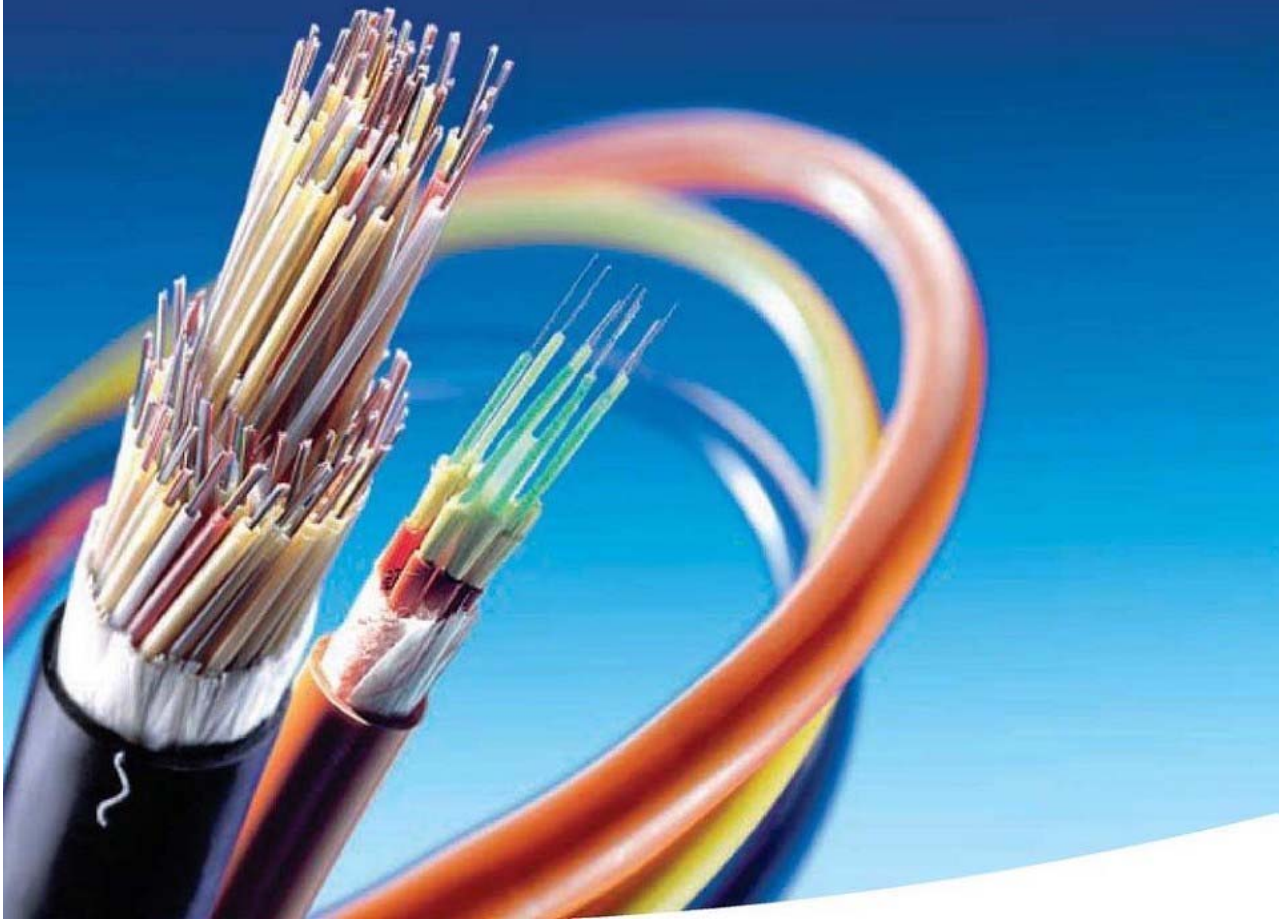
Fiber optics

An optical fiber cable is a cable containing one or more optical fibers that are used to carry light. The optical fiber elements are typically individually coated with plastic layers and contained in a protective tube suitable for the environment where the cable will be deployed. Different types of cable are used for different applications, for example long distance telecommunication, or providing a high-speed data connection between different parts of a building.

Fiber optics used for long distance, hard to splice, not vulnerable to cross talk and difficult to tap. It supports voice data, image and video.

Fiber Optics

Fiber Optic Cables



Radio System

Radio systems are used for short distance, cheap and easy to intercept. Radio is the radiation (wireless transmission) of electromagnetic signals through the atmosphere or free space.

Information, such as sound, is carried by systematically changing (modulating) some property of the radiated waves, such as their amplitude, frequency, phase, or pulse width. When radio waves strike an electrical conductor, the oscillating fields induce an alternating current in the conductor. The information in the waves can be extracted and transformed back into its original form.

Microwave radio system

Microwave transmission refers to the technology of transmitting information or energy by the use of radio waves whose wavelengths are conveniently measured in small numbers of centimeter; these are called microwaves.

Microwaves are widely used for point-to-point communications because their small wavelength allows conveniently-sized antennas to direct them in narrow beams, which can be pointed directly at the receiving antenna. This allows nearby microwave equipment to use the same frequencies without interfering with each other, as lower frequency radio waves do. Another advantage is that the high frequency of microwaves gives the microwave band a very large information-carrying capacity; the microwave band has a bandwidth 30 times that of all the rest of the radio spectrum below it. A disadvantage is that microwaves are limited to line of sight propagation; they cannot pass around hills or mountains as lower frequency radio waves can.

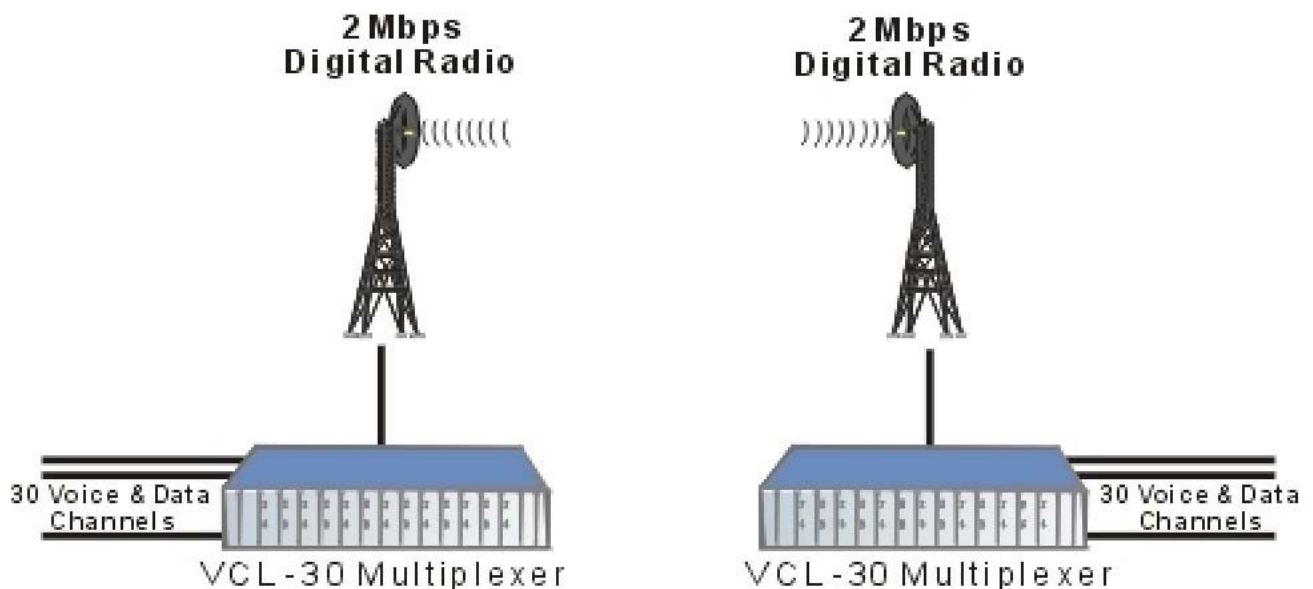
Microwave radio transmission is commonly used in point-to-point communication systems on the surface of the Earth, in satellite communications, and in deep space radio communications. Other parts of the microwave radio band are used for radars, radio navigation systems, sensor systems, and radio astronomy.

Microwave radio systems are carriers for voice data signal, cheap and easy to tap.

Microwave Radio System

VCL-30 E1, 2Mbps Multiplexer

Digital Microwave Radio Link



Satellite Radio Link

Satellite radio is a radio service broadcast from satellites primarily to cars, with the signal broadcast nationwide, across a much wider geographical area than terrestrial radio stations. It is available by subscription, mostly commercial free, and offers subscribers more stations and a wider variety of programming options than terrestrial radio.

Satellite radio link uses transponder to send information and easy to intercept.

The following answers are incorrect:

Fiber optics - Fiber optics cables are used for long distance, hard to splice, not vulnerable to cross talk and difficult to tap. It supports voice data, image and video.

Radio System - Radio systems are used for short distance, cheap and easy to tap.

Satellite Radio Link - Satellite radio link uses transponder to send information and easy to tap.
CISA review manual 2014 page number 265

QUESTION 444

Which of the following transmission media is MOST difficult to tap?

- A. Copper cable
- B. Fiber Optics
- C. Satellite Radio Link
- D. Radio System

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support
Fiber optics cables are used for long distance, hard to splice, not vulnerable to cross talk and difficult to tap. It supports voice data, image and video.

For your exam you should know below information about transmission media:

Copper Cable

Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data.

Copper has been used in electric wiring since the invention of the electromagnet and the telegraph in the 1820s. The invention of the telephone in 1876 created further demand for copper wire as an electrical conductor.

Copper is the electrical conductor in many categories of electrical wiring. Copper wire is used in power generation, power transmission, power distribution, telecommunications, electronics circuitry, and countless types of electrical equipment. Copper and its alloys are also used to make electrical contacts. Electrical wiring in buildings is the most important market for the copper industry. Roughly half of all copper mined is used to manufacture electrical wire and cable conductors.

Copper Cable



Coaxial cable

Coaxial cable, or coax (pronounced 'ko.aks), is a type of cable that has an inner conductor surrounded by a tubular insulating layer, surrounded by a tubular conducting shield. Many coaxial cables also have an insulating outer sheath or jacket. The term coaxial comes from the inner conductor and the outer shield sharing a geometric axis. Coaxial cable was invented by English engineer and mathematician Oliver Heaviside, who patented the design in 1880. Coaxial cable differs from other shielded cable used for carrying lower-frequency signals, such as audio signals, in that the dimensions of the cable are controlled to give a precise, constant conductor spacing, which is needed for it to function efficiently as a radio frequency transmission line.

Coaxial cable is expensive and does not support many LAN's. It supports data and video.



Coaxial Cable

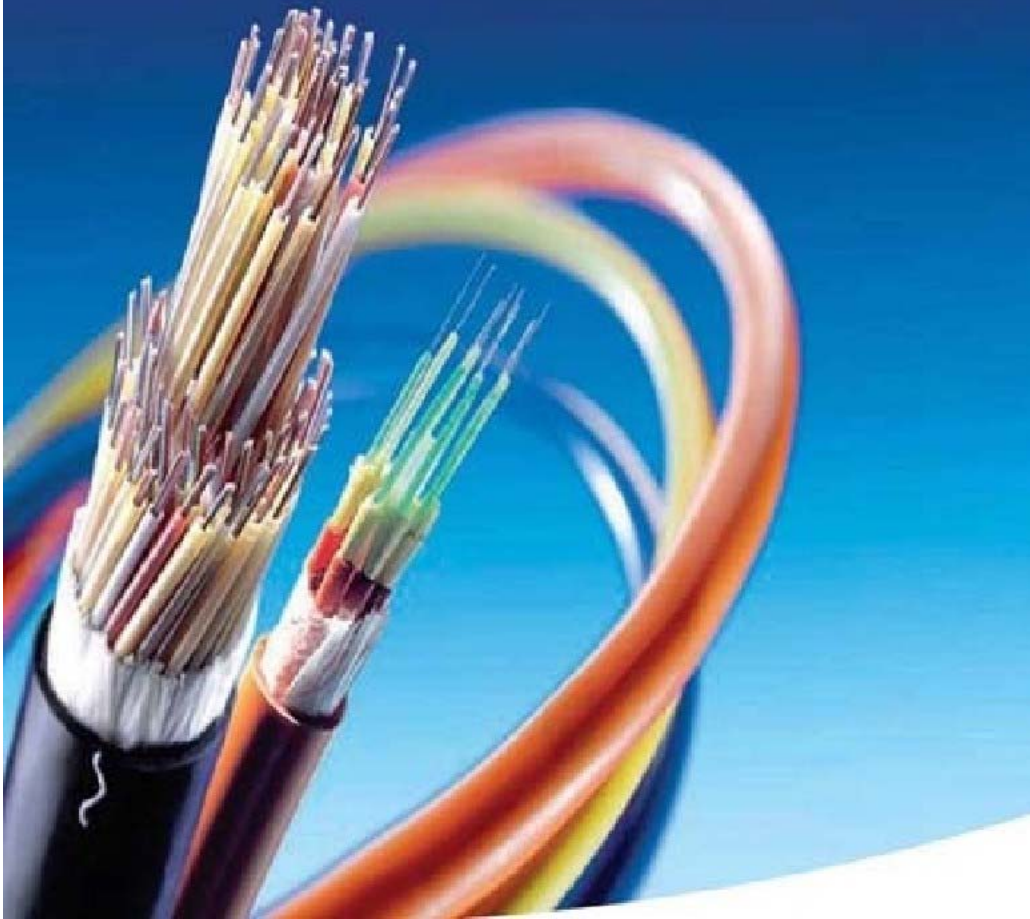
Fiber optics

An optical fiber cable is a cable containing one or more optical fibers that are used to carry light. The optical fiber elements are typically individually coated with plastic layers and contained in a protective tube suitable for the environment where the cable will be deployed. Different types of cable are used for different applications, for example long distance telecommunication, or providing a high-speed data connection between different parts of a building.

Fiber optics used for long distance, hard to splice, not vulnerable to cross talk and difficult to tap. It supports voice data, image and video.

Fiber Optics

Fiber Optic Cables



Microwave radio system

Microwave transmission refers to the technology of transmitting information or energy by the use of radio waves whose wavelengths are conveniently measured in small numbers of centimeter; these are called microwaves.

Microwaves are widely used for point-to-point communications because their small wavelength allows conveniently-sized antennas to direct them in narrow beams, which can be pointed directly at the receiving antenna. This allows nearby microwave equipment to use the same frequencies without interfering with each other, as lower frequency radio waves do. Another advantage is that the high frequency of microwaves gives the microwave band a very large information-carrying capacity; the microwave band has a bandwidth 30 times that of all the rest of the radio spectrum below it. A disadvantage is that microwaves are limited to line of sight propagation; they cannot pass around hills or mountains as lower frequency radio waves can.

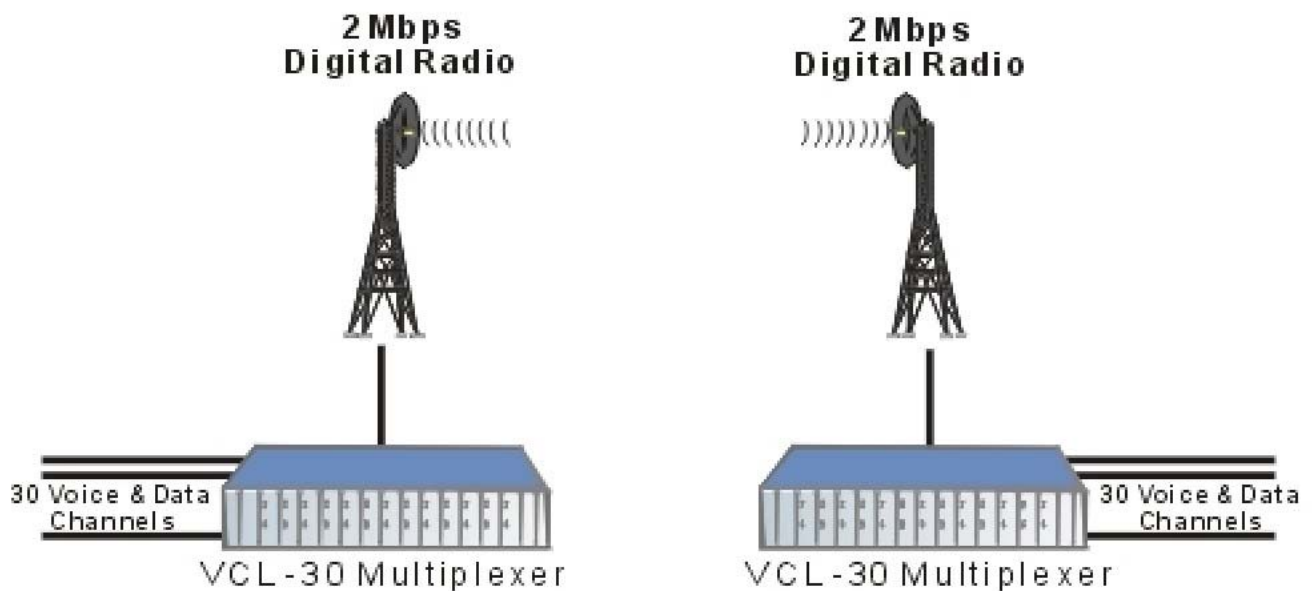
Microwave radio transmission is commonly used in point-to-point communication systems on the surface of the Earth, in satellite communications, and in deep space radio communications. Other parts of the microwave radio band are used for radars, radio navigation systems, sensor systems, and radio astronomy.

Microwave radio systems are carriers for voice data signal, cheap and easy to intercept.

Microwave Radio System

VCL-30 E1, 2Mbps Multiplexer

Digital Microwave Radio Link



Satellite Radio Link

Satellite radio is a radio service broadcast from satellites primarily to cars, with the signal broadcast nationwide, across a much wider geographical area than terrestrial radio stations. It is available by subscription, mostly commercial free, and offers subscribers more stations and a wider variety of programming options than terrestrial radio.

Satellite radio link uses transponder to send information and easy to intercept.

Radio System

Radio systems are used for short distance, cheap and easy to intercept. Radio is the radiation (wireless transmission) of electromagnetic signals through the atmosphere or free space.

Information, such as sound, is carried by systematically changing (modulating) some property of the radiated waves, such as their amplitude, frequency, phase, or pulse width. When radio waves strike an electrical conductor, the oscillating fields induce an alternating current in the conductor. The information in the waves can be extracted and transformed back into its original form.

The following answers are incorrect:

Copper Cable- Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data.

Radio System - Radio systems are used for short distance, cheap and easy to tap.

Satellite Radio Link - Satellite radio link uses transponder to send information and easy to tap.
CISA review manual 2014 page number 265

QUESTION 445

Which of the following transmission media uses a transponder to send information?

- A. Copper cable
- B. Fiber Optics
- C. Satellite Radio Link
- D. Coaxial cable

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Satellite radio link uses transponder to send information and are easy to intercept.

For your exam you should know below information about transmission media:

Copper Cable

Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data.

Copper has been used in electric wiring since the invention of the electromagnet and the telegraph in the 1820s. The invention of the telephone in 1876 created further demand for copper wire as an electrical conductor.

Copper is the electrical conductor in many categories of electrical wiring. Copper wire is used in power generation, power transmission, power distribution, telecommunications, electronics circuitry, and countless types of electrical equipment. Copper and its alloys are also used to make electrical contacts. Electrical wiring in buildings is the most important market for the copper industry. Roughly half of all copper mined is used to manufacture electrical wire and cable conductors.

Copper Cable



Coaxial cable

Coaxial cable, or coax (pronounced 'ko.aks), is a type of cable that has an inner conductor surrounded by a tubular insulating layer, surrounded by a tubular conducting shield. Many coaxial cables also have an insulating outer sheath or jacket. The term coaxial comes from the inner conductor and the outer shield sharing a geometric axis. Coaxial cable was invented by English engineer and mathematician Oliver Heaviside, who patented the design in 1880. Coaxial cable differs from other shielded cable used for carrying lower-frequency signals, such as audio signals, in that the dimensions of the cable are controlled to give a precise, constant conductor spacing, which is needed for it to function efficiently as a radio frequency transmission line.

Coaxial cable is expensive and does not support many LAN's. It supports data and video.



Coaxial Cable

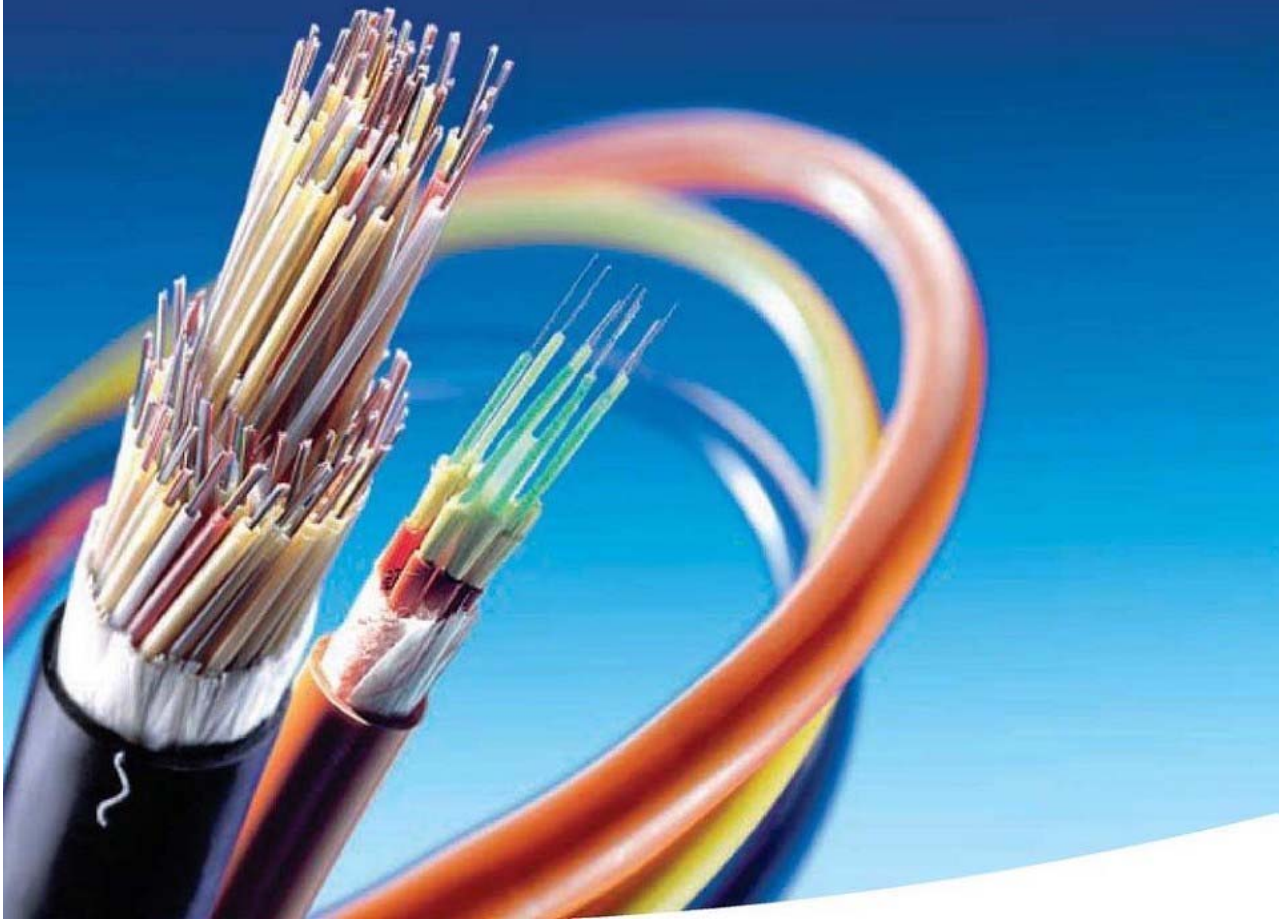
Fiber optics

An optical fiber cable is a cable containing one or more optical fibers that are used to carry light. The optical fiber elements are typically individually coated with plastic layers and contained in a protective tube suitable for the environment where the cable will be deployed. Different types of cable are used for different applications, for example long distance telecommunication, or providing a high-speed data connection between different parts of a building.

Fiber optics used for long distance, hard to splice, not vulnerable to cross talk and difficult to tap. It supports voice data, image and video.

Fiber Optics

Fiber Optic Cables



Microwave radio system

Microwave transmission refers to the technology of transmitting information or energy by the use of radio waves whose wavelengths are conveniently measured in small numbers of centimeter; these are called microwaves.

Microwaves are widely used for point-to-point communications because their small wavelength allows conveniently-sized antennas to direct them in narrow beams, which can be pointed directly at the receiving antenna. This allows nearby microwave equipment to use the same frequencies without interfering with each other, as lower frequency radio waves do. Another advantage is that the high frequency of microwaves gives the microwave band a very large information-carrying capacity; the microwave band has a bandwidth 30 times that of all the rest of the radio spectrum below it. A disadvantage is that microwaves are limited to line of sight propagation; they cannot pass around hills or mountains as lower frequency radio waves can.

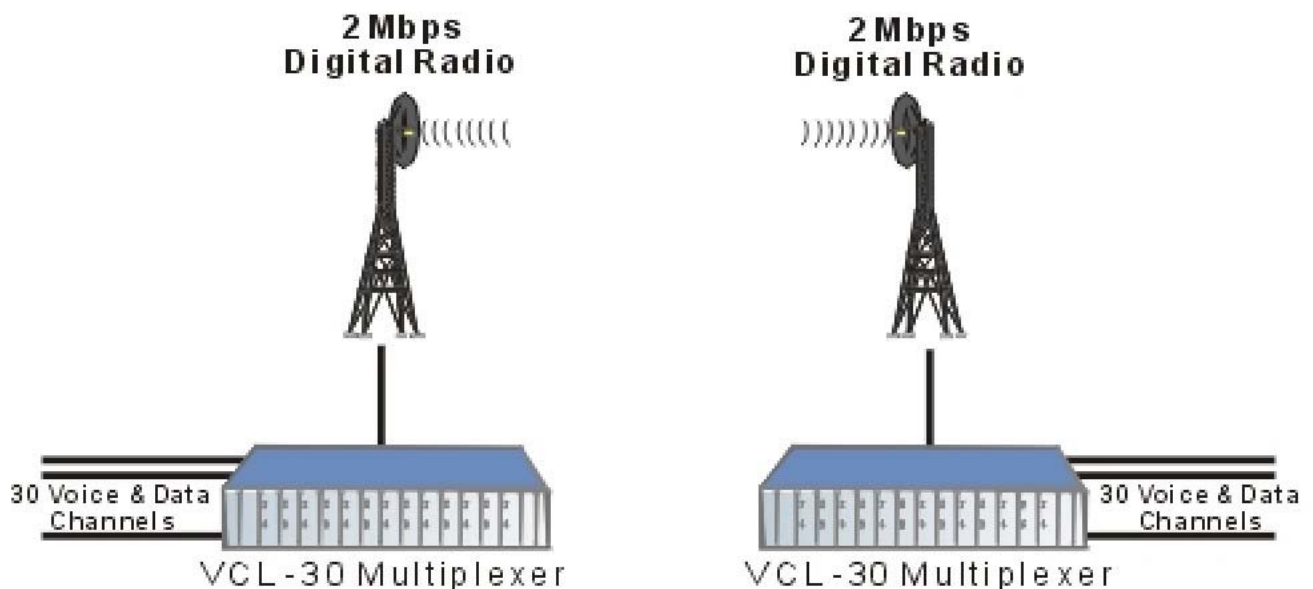
Microwave radio transmission is commonly used in point-to-point communication systems on the surface of the Earth, in satellite communications, and in deep space radio communications. Other parts of the microwave radio band are used for radars, radio navigation systems, sensor systems, and radio astronomy.

Microwave radio systems are carriers for voice data signal, cheap and easy to intercept.

Microwave Radio System

VCL-30 E1, 2Mbps Multiplexer

Digital Microwave Radio Link



Satellite Radio Link

Satellite radio is a radio service broadcast from satellites primarily to cars, with the signal broadcast nationwide, across a much wider geographical area than terrestrial radio stations. It is available by subscription, mostly commercial free, and offers subscribers more stations and a wider variety of programming options than terrestrial radio.

Satellite radio link uses transponder to send information and easy to intercept.

Radio System

Radio systems are used for short distance, cheap and easy to intercept. Radio is the radiation (wireless transmission) of electromagnetic signals through the atmosphere or free space.

Information, such as sound, is carried by systematically changing (modulating) some property of the radiated waves, such as their amplitude, frequency, phase, or pulse width. When radio waves strike an electrical conductor, the oscillating fields induce an alternating current in the conductor. The information in the waves

can be extracted and transformed back into its original form.

The following answers are incorrect:

Copper Cable- Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data.

Radio System - Radio systems are used for short distance, cheap and easy to tap.

Satellite Radio Link - Satellite radio link uses transponder to send information and easy to tap.
CISA review manual 2014 page number 265

QUESTION 446

Which of the following transmission media is LEAST vulnerable to cross talk?

- A. Copper cable
- B. Fiber Optics
- C. Satellite Radio Link
- D. Coaxial cable

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Fiber optics cables are used for long distance, hard to splice, not vulnerable to cross talk and difficult to tap. It supports voice data, image and video.

For your exam you should know below information about transmission media:

Copper Cable

Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data.

Copper has been used in electric wiring since the invention of the electromagnet and the telegraph in the 1820s. The invention of the telephone in 1876 created further demand for copper wire as an electrical conductor.

Copper is the electrical conductor in many categories of electrical wiring. Copper wire is used in power generation, power transmission, power distribution, telecommunications, electronics circuitry, and countless types of electrical equipment. Copper and its alloys are also used to make electrical contacts. Electrical wiring in buildings is the most important market for the copper industry. Roughly half of all copper mined is used to manufacture electrical wire and cable conductors.

Copper Cable



Coaxial cable

Coaxial cable, or coax (pronounced 'ko.aks), is a type of cable that has an inner conductor surrounded by a tubular insulating layer, surrounded by a tubular conducting shield. Many coaxial cables also have an insulating outer sheath or jacket. The term coaxial comes from the inner conductor and the outer shield sharing a geometric axis. Coaxial cable was invented by English engineer and mathematician Oliver Heaviside, who patented the design in 1880. Coaxial cable differs from other shielded cable used for carrying lower-frequency signals, such as audio signals, in that the dimensions of the cable are controlled to give a precise, constant conductor spacing, which is needed for it to function efficiently as a radio frequency transmission line.

Coaxial cable is expensive and does not support many LAN's. It supports data and video.

Coaxial Cable



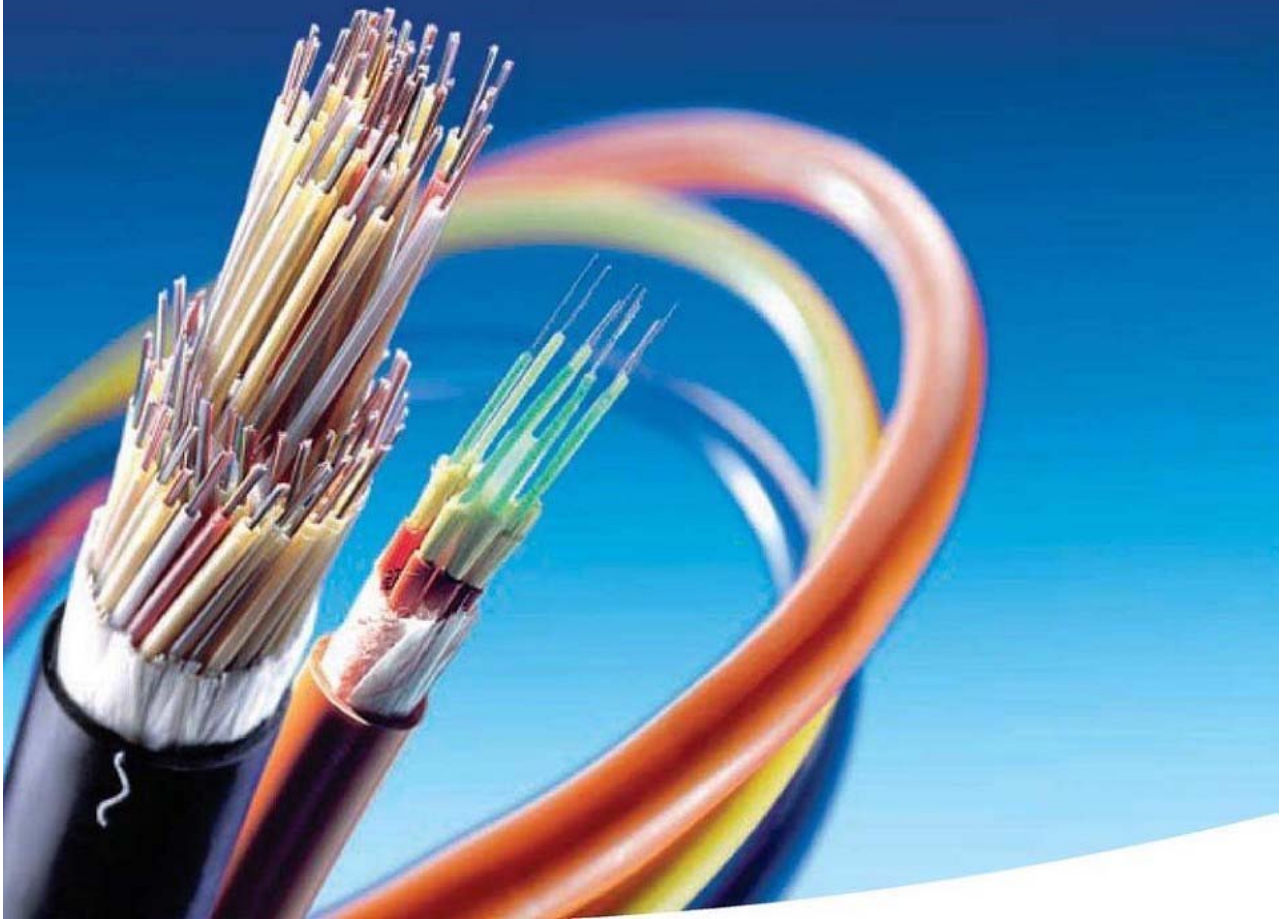
Fiber optics

An optical fiber cable is a cable containing one or more optical fibers that are used to carry light. The optical fiber elements are typically individually coated with plastic layers and contained in a protective tube suitable for the environment where the cable will be deployed. Different types of cable are used for different applications, for example long distance telecommunication, or providing a high-speed data connection between different parts of a building.

Fiber optics used for long distance, hard to splice, not vulnerable to cross talk and difficult to tap. It supports voice data, image and video.

Fiber Optics

Fiber Optic Cables



Microwave radio system

Microwave transmission refers to the technology of transmitting information or energy by the use of radio waves whose wavelengths are conveniently measured in small numbers of centimeter; these are called microwaves.

Microwaves are widely used for point-to-point communications because their small wavelength allows conveniently-sized antennas to direct them in narrow beams, which can be pointed directly at the receiving antenna. This allows nearby microwave equipment to use the same frequencies without interfering with each other, as lower frequency radio waves do. Another advantage is that the high frequency of microwaves gives the microwave band a very large information-carrying capacity; the microwave band has a bandwidth 30 times that of all the rest of the radio spectrum below it. A disadvantage is that microwaves are limited to line of sight propagation; they cannot pass around hills or mountains as lower frequency radio waves can.

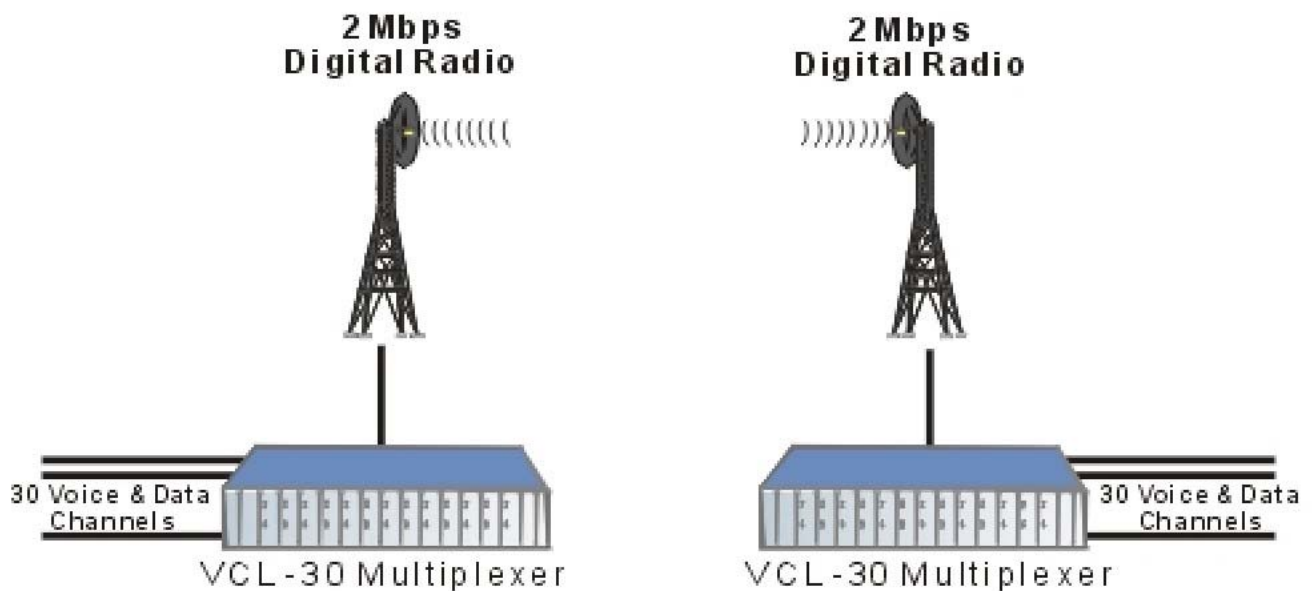
Microwave radio transmission is commonly used in point-to-point communication systems on the surface of the Earth, in satellite communications, and in deep space radio communications. Other parts of the microwave radio band are used for radars, radio navigation systems, sensor systems, and radio astronomy.

Microwave radio systems are carriers for voice data signal, cheap and easy to intercept.

Microwave Radio System

VCL-30 E1, 2Mbps Multiplexer

Digital Microwave Radio Link



Satellite Radio Link

Satellite radio is a radio service broadcast from satellites primarily to cars, with the signal broadcast nationwide, across a much wider geographical area than terrestrial radio stations. It is available by subscription, mostly commercial free, and offers subscribers more stations and a wider variety of programming options than terrestrial radio.

Satellite radio link uses transponder to send information and easy to intercept.

Radio System

Radio systems are used for short distance, cheap and easy to tap. Radio is the radiation (wireless transmission) of electromagnetic signals through the atmosphere or free space.

Information, such as sound, is carried by systematically changing (modulating) some property of the radiated

waves, such as their amplitude, frequency, phase, or pulse width. When radio waves strike an electrical conductor, the oscillating fields induce an alternating current in the conductor. The information in the waves can be extracted and transformed back into its original form.

The following answers are incorrect:

Copper Cable- Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data.

Satellite Radio Link - Satellite radio link uses transponder to send information and easy to tap.

Coaxial cable - Coaxial cable are expensive and does not support many LAN's. It supports data and video CISA review manual 2014 page number 265

QUESTION 447

In which of the following transmission media it is MOST difficult to modify the information traveling across the network?

- A. Copper cable
- B. Fiber Optics
- C. Satellite Radio Link
- D. Coaxial cable

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Fiber optics cables are used for long distance, hard to splice, not vulnerable to cross talk and difficult to tap. It supports voice data, image and video.

For your exam you should know below information about transmission media:

Copper Cable

Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data.

Copper has been used in electric wiring since the invention of the electromagnet and the telegraph in the 1820s. The invention of the telephone in 1876 created further demand for copper wire as an electrical conductor.

Copper is the electrical conductor in many categories of electrical wiring. Copper wire is used in power generation, power transmission, power distribution, telecommunications, electronics circuitry, and countless types of electrical equipment. Copper and its alloys are also used to make electrical contacts. Electrical wiring in buildings is the most important market for the copper industry. Roughly half of all copper mined is used to manufacture electrical wire and cable conductors.

Copper Cable



Coaxial cable

Coaxial cable, or coax (pronounced 'ko.aks), is a type of cable that has an inner conductor surrounded by a tubular insulating layer, surrounded by a tubular conducting shield. Many coaxial cables also have an insulating outer sheath or jacket. The term coaxial comes from the inner conductor and the outer shield sharing a geometric axis. Coaxial cable was invented by English engineer and mathematician Oliver Heaviside, who patented the design in 1880. Coaxial cable differs from other shielded cable used for carrying lower-frequency signals, such as audio signals, in that the dimensions of the cable are controlled to give a precise, constant conductor spacing, which is needed for it to function efficiently as a radio frequency transmission line. Coaxial cable is expensive and does not support many LAN's. It supports data and video.

Coaxial Cable



Fiber optics

An optical fiber cable is a cable containing one or more optical fibers that are used to carry light. The optical fiber elements are typically individually coated with plastic layers and contained in a protective tube suitable for the environment where the cable will be deployed. Different types of cable are used for different applications, for example long distance telecommunication, or providing a high-speed data connection between different parts of a building.

Fiber optics used for long distance, hard to splice, not vulnerable to cross talk and difficult to tap. It supports voice data, image and video.

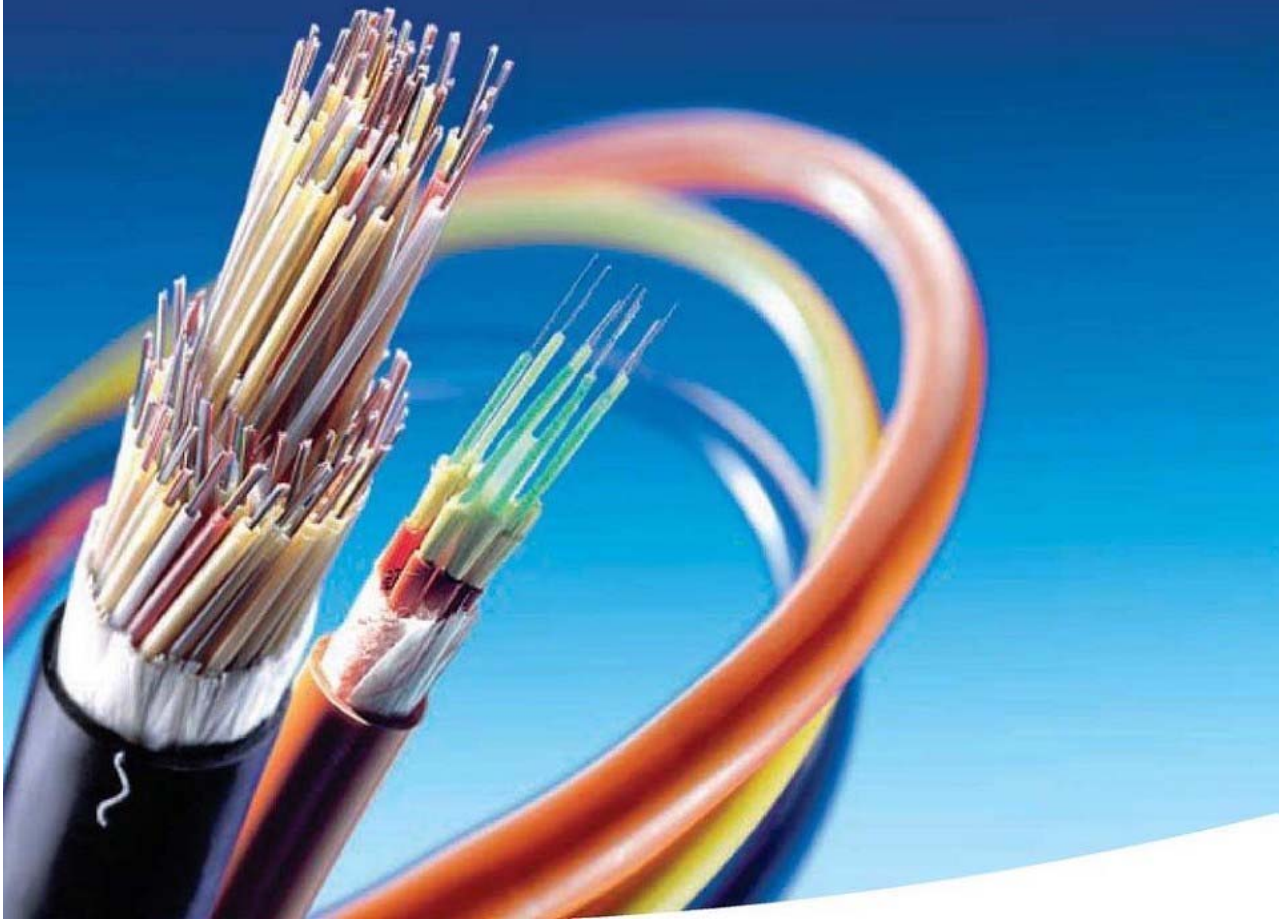
Radio System

Radio systems are used for short distance, cheap and easy to tap. Radio is the radiation (wireless transmission) of electromagnetic signals through the atmosphere or free space.

Information, such as sound, is carried by systematically changing (modulating) some property of the radiated waves, such as their amplitude, frequency, phase, or pulse width. When radio waves strike an electrical conductor, the oscillating fields induce an alternating current in the conductor. The information in the waves can be extracted and transformed back into its original form.

Fiber Optics

Fiber Optic Cables



Microwave radio system

Microwave transmission refers to the technology of transmitting information or energy by the use of radio waves whose wavelengths are conveniently measured in small numbers of centimeter; these are called microwaves.

Microwaves are widely used for point-to-point communications because their small wavelength allows conveniently-sized antennas to direct them in narrow beams, which can be pointed directly at the receiving antenna. This allows nearby microwave equipment to use the same frequencies without interfering with each other, as lower frequency radio waves do. Another advantage is that the high frequency of microwaves gives the microwave band a very large information-carrying capacity; the microwave band has a bandwidth 30 times that of all the rest of the radio spectrum below it. A disadvantage is that microwaves are limited to line of sight propagation; they cannot pass around hills or mountains as lower frequency radio waves can.

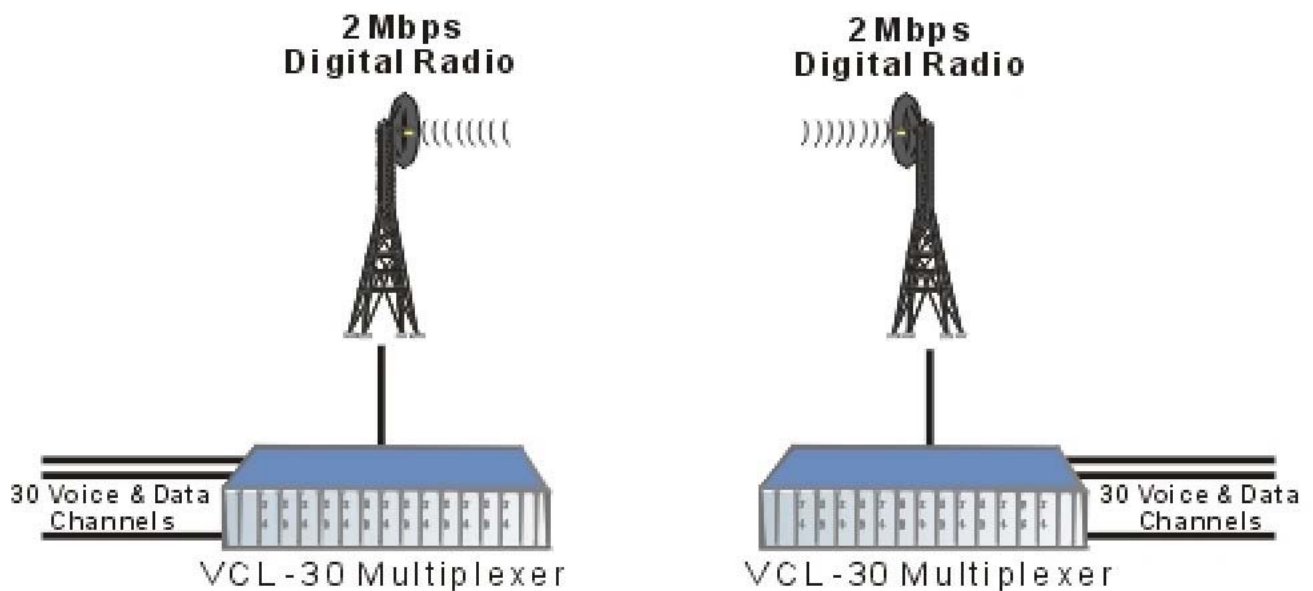
Microwave radio transmission is commonly used in point-to-point communication systems on the surface of the Earth, in satellite communications, and in deep space radio communications. Other parts of the microwave radio band are used for radars, radio navigation systems, sensor systems, and radio astronomy.

Microwave radio systems are carriers for voice data signal, cheap and easy to tap.

Microwave Radio System

VCL-30 E1, 2Mbps Multiplexer

Digital Microwave Radio Link



Satellite Radio Link

Satellite radio is a radio service broadcast from satellites primarily to cars, with the signal broadcast nationwide, across a much wider geographical area than terrestrial radio stations. It is available by subscription, mostly commercial free, and offers subscribers more stations and a wider variety of programming options than terrestrial radio.

Satellite radio link uses transponder to send information and easy to tap.

The following answers are incorrect:

Copper Cable- Copper cable is very simple to install and easy to tap. It is used mostly for short distance and supports voice and data.

Satellite Radio Link - Satellite radio link uses transponder to send information and easy to tap.

Coaxial cable - Coaxial cable are expensive and does not support many LAN's. It supports data and video CISA review manual 2014 page number 265

QUESTION 448

Which of the following is the INCORRECT Layer to Protocol mapping used in the DOD TCP/IP model?

- A. Application layer Telnet
- B. Transport layer ICMP
- C. Internet layer IP
- D. Network Access layer Ethernet

Correct Answer: B

Explanation

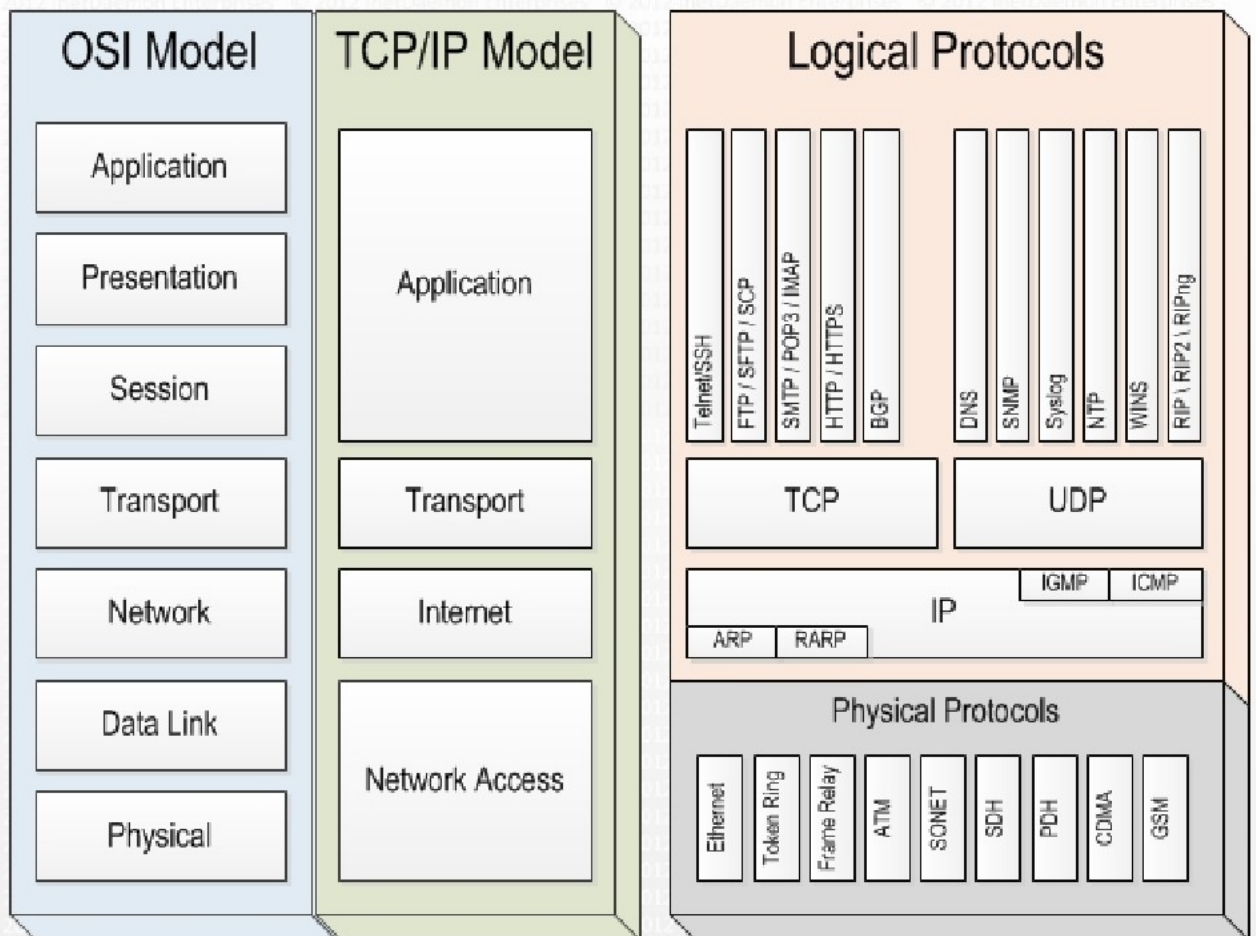
Explanation/Reference:

Section: Information System Operations, Maintenance and Support The keyword INCORRECT is used within the question. You need to find out the incorrect Layer to Protocol mapping.

The ICMP protocol works at Internet layer of the DoD TCP/IP model, not at the Transport Layer.

For your exam you should know below information about the TCP/IP models:
Network Models

NETWORK MODELS



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

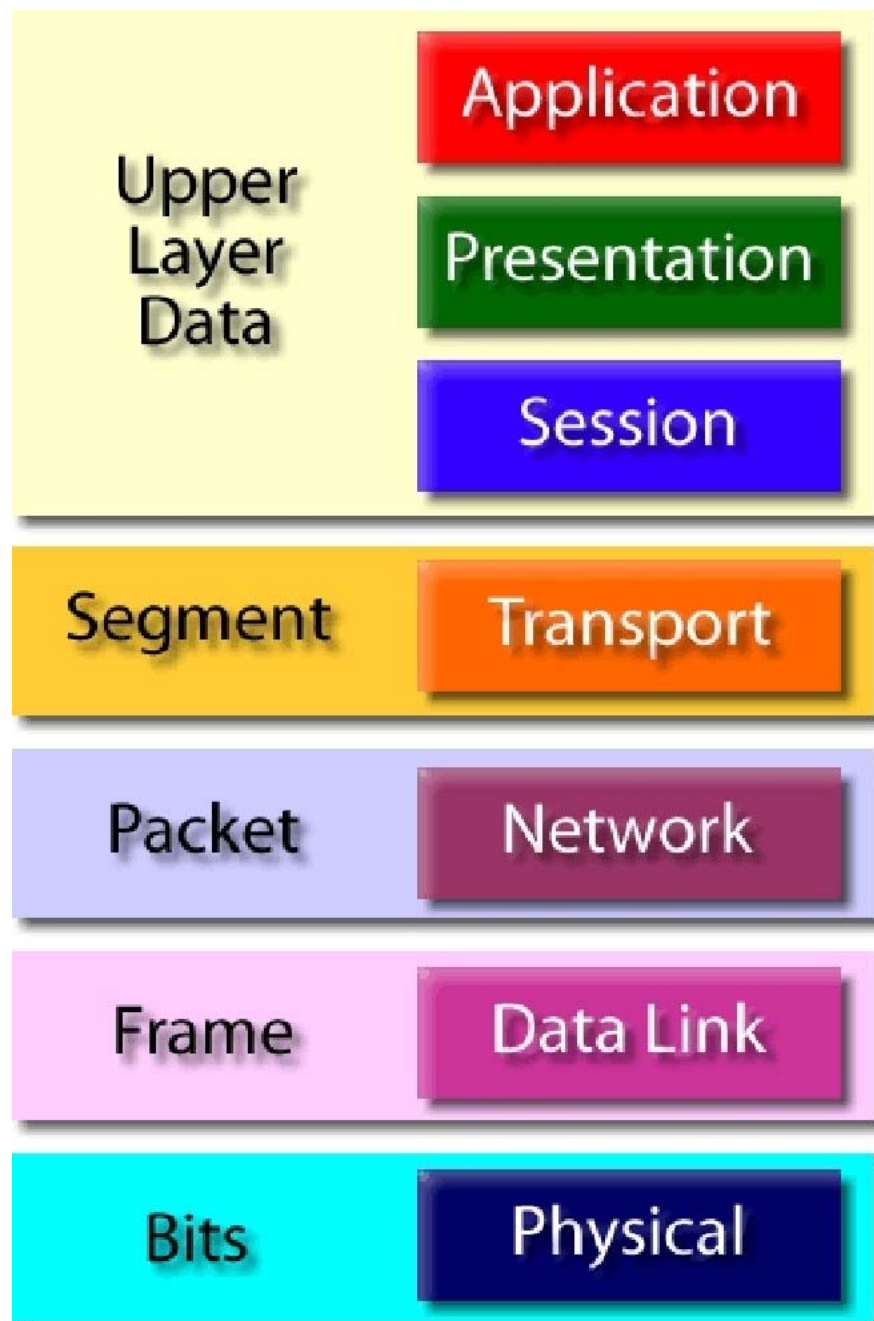
Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/ Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

The other options correctly describe the Layer to Protocol mapping of the DoD TCP/IP model protocols. CISA review manual 2014 page number 272

QUESTION 449

Which of the following protocol does NOT work at the Application layer of the TCP/IP Models?

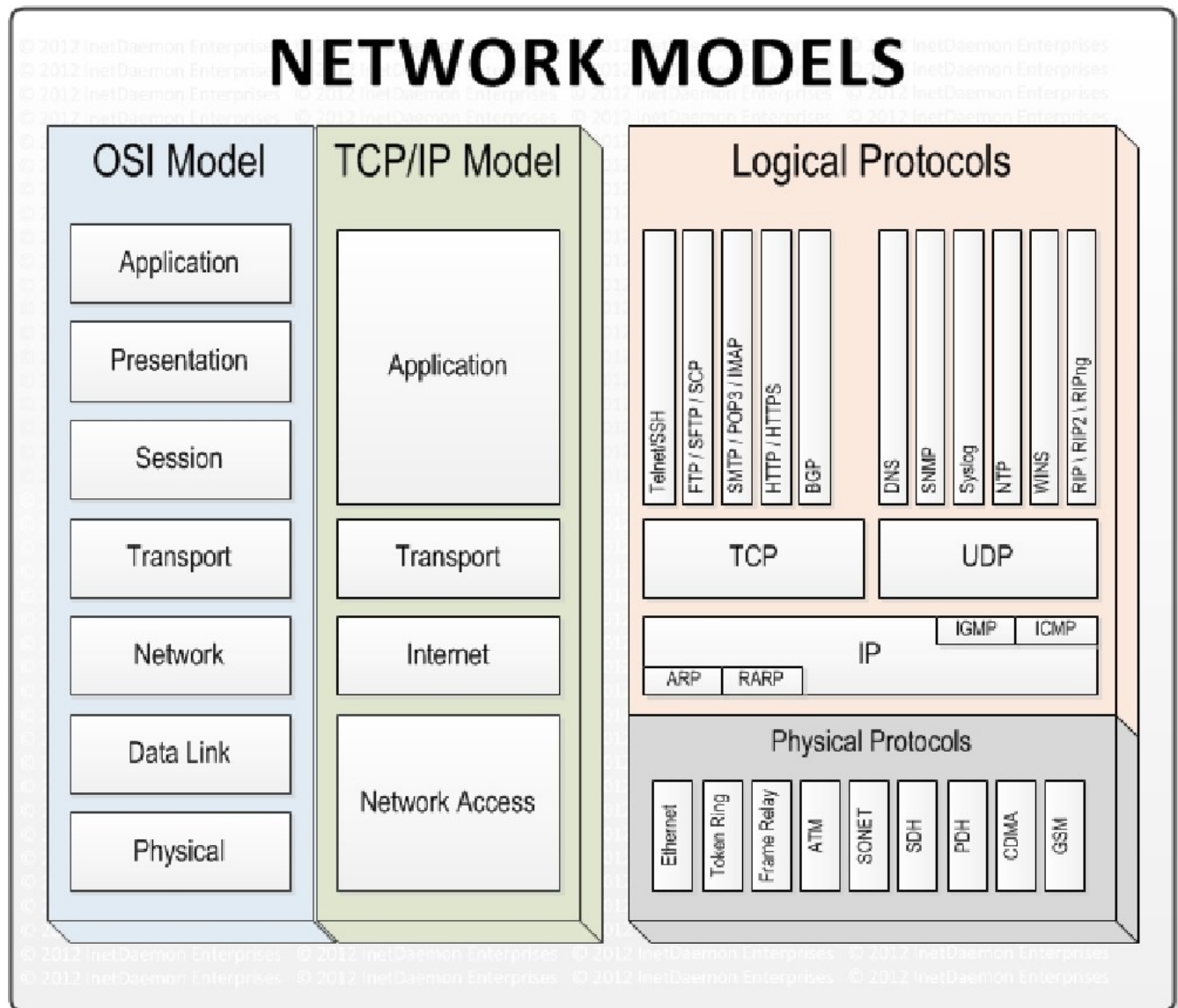
- A. HTTP
- B. FTP
- C. NTP
- D. TCP

Correct Answer: D
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The NOT keyword is used in the question. You need to find out a protocol which does not work at application layer. TCP protocol works at transport layer of a TCP/IP models.

For your exam you should know below information about TCP/IP model:
Network Models

**Layer 4. Application Layer**

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

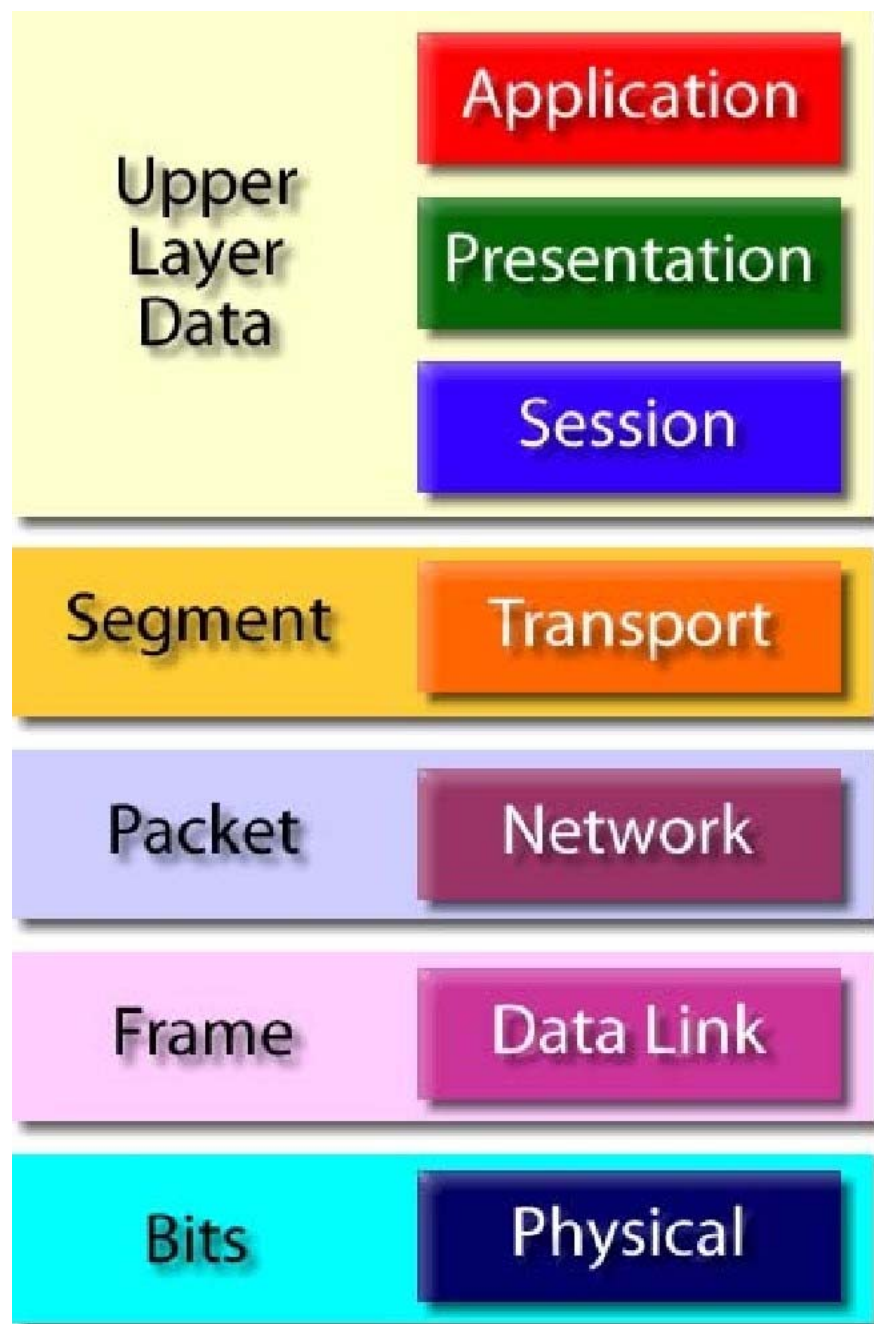
Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/ Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

HTTP, FTP and NTP protocols works at application layer in TCP/IP model.
CISA review manual 2014 page number 272

QUESTION 450

Which of the following statement INCORRECTLY describes device and where they sit within the TCP/IP model?

A. Layer 4 switch work at Network interface layer in TCP/IP model

- B. Router works at Network interface layer in TCP/IP model
- C. Layer 3 switch work at Network interface layer in TCP/IP model
- D. Hub works at LAN or WAN interface layer of a TCP/IP model

Correct Answer: A

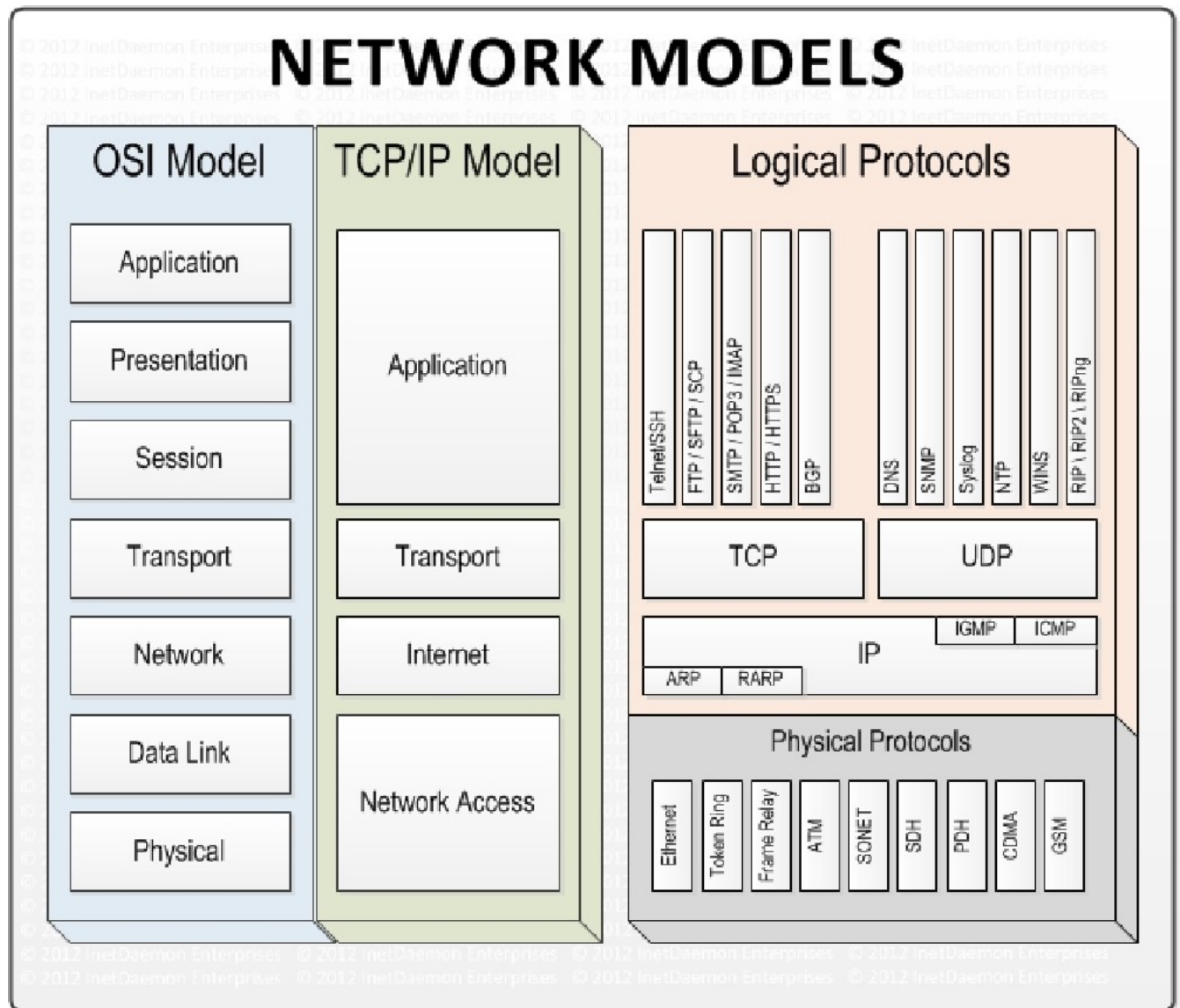
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The keyword within the question is INCORRECTLY. You need to find out incorrect statement.

For your exam you should know below information about TCP/IP model:

Network models



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into

any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

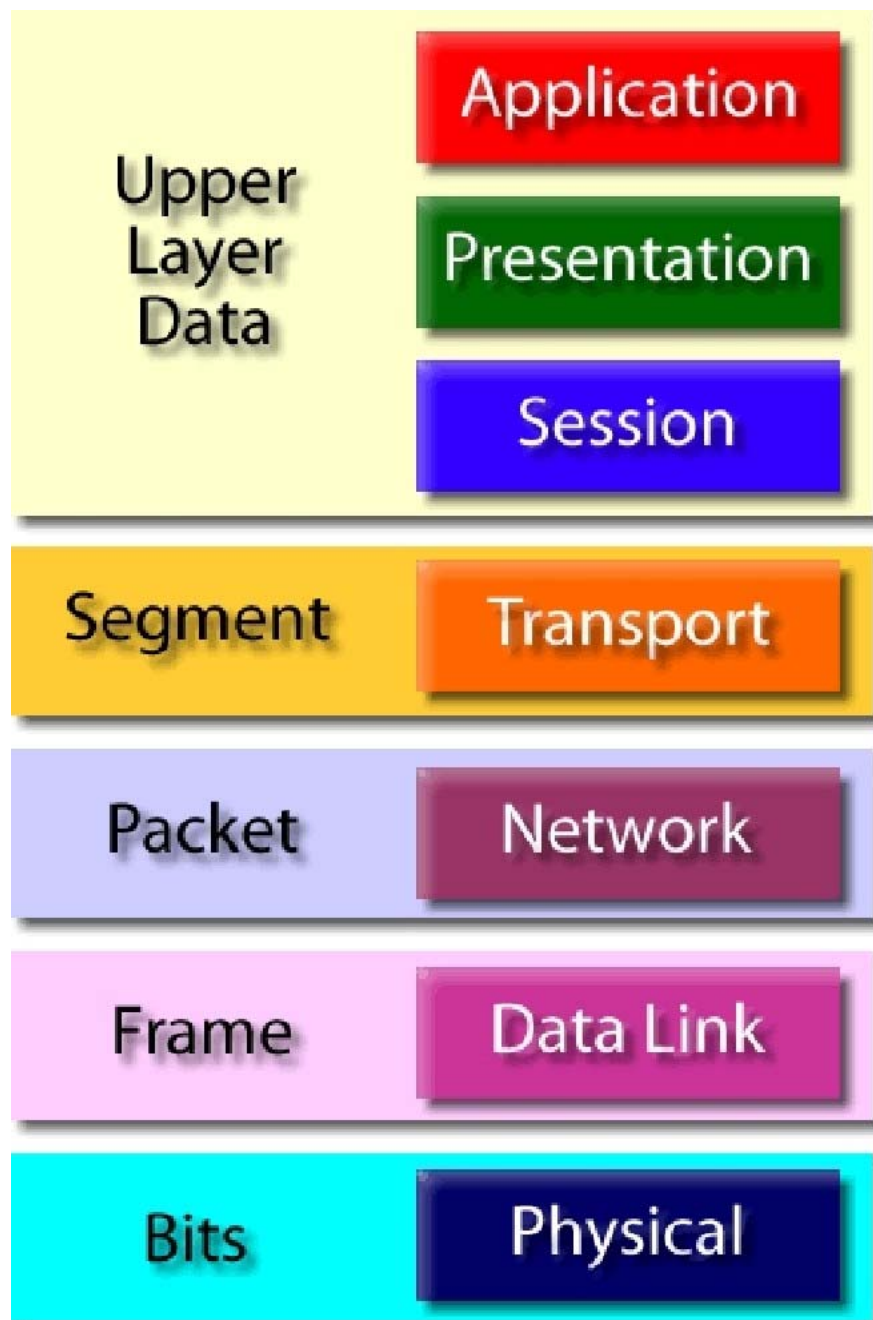
The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/ Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will

wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

QUESTION 451

Which of the following protocol does NOT work at Network interface layer in TCP/IP model?

- A. ICMP
- B. DNS
- C. ARP
- D. Internet protocol

Correct Answer: B

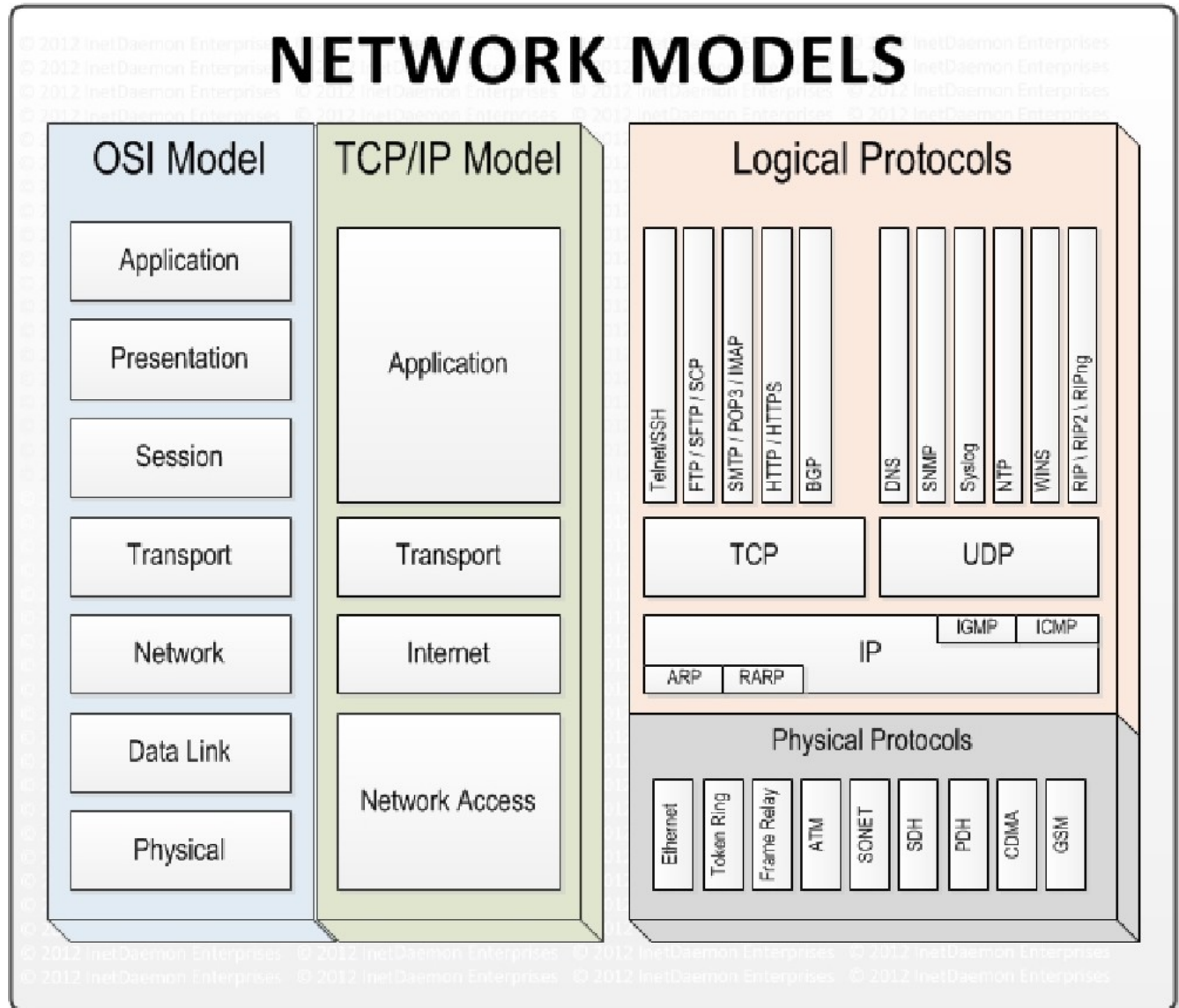
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The NOT is the keyword used in the question. You need to find out a protocol which does not work at network interface layer in TCP/IP model. DNS protocol works at application layer of a TCP/IP model.

For your exam you should know below information about TCP/IP model:

Network models



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

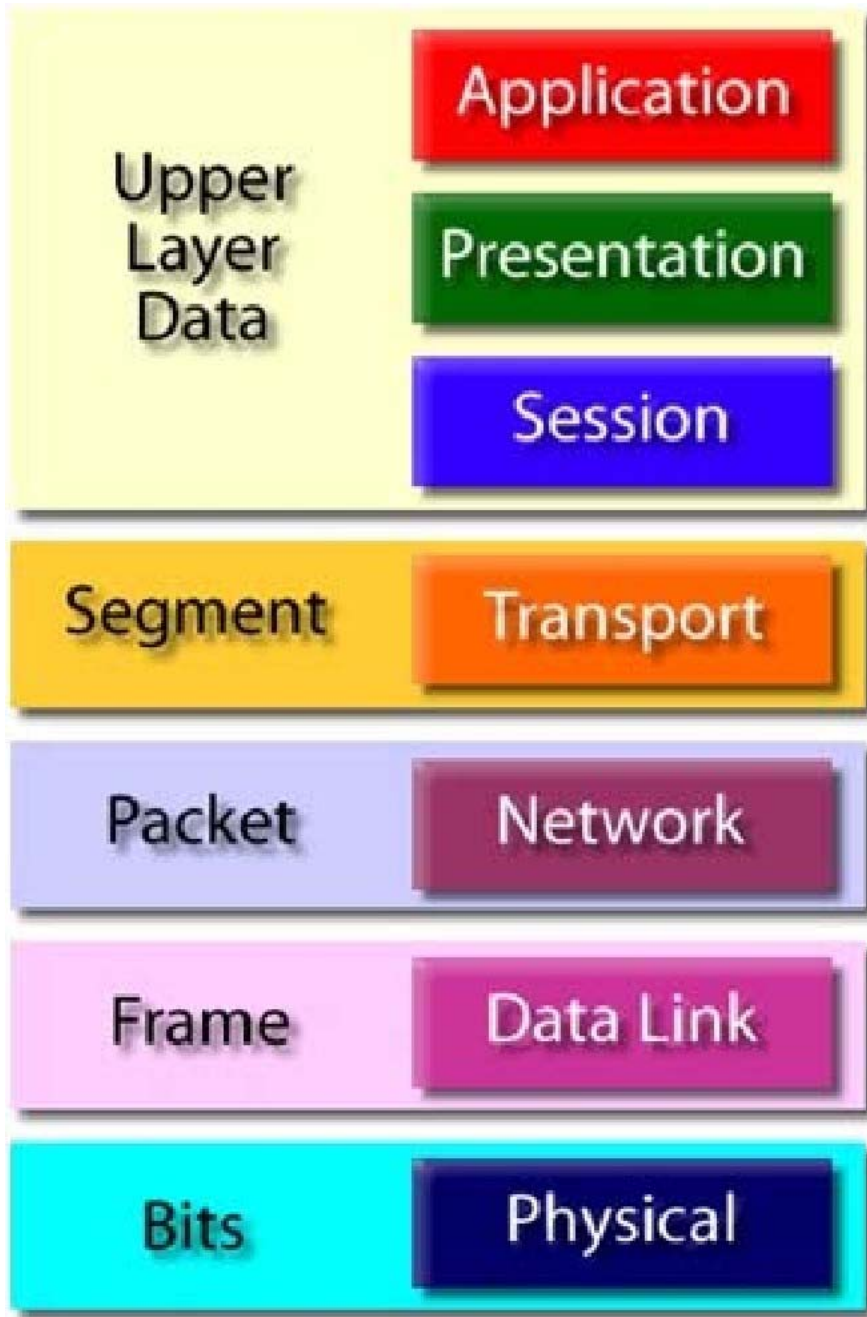
Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/ Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

ICMP, ARP and Internet protocol works at Network interface layer of a TCP/IP model.
CISA review manual 2014 page number 272

QUESTION 452

Which of the following is the protocol data unit (PDU) of application layer in TCP/IP model?

- A. Data
- B. Segment
- C. Packet
- D. Frame

Correct Answer: A

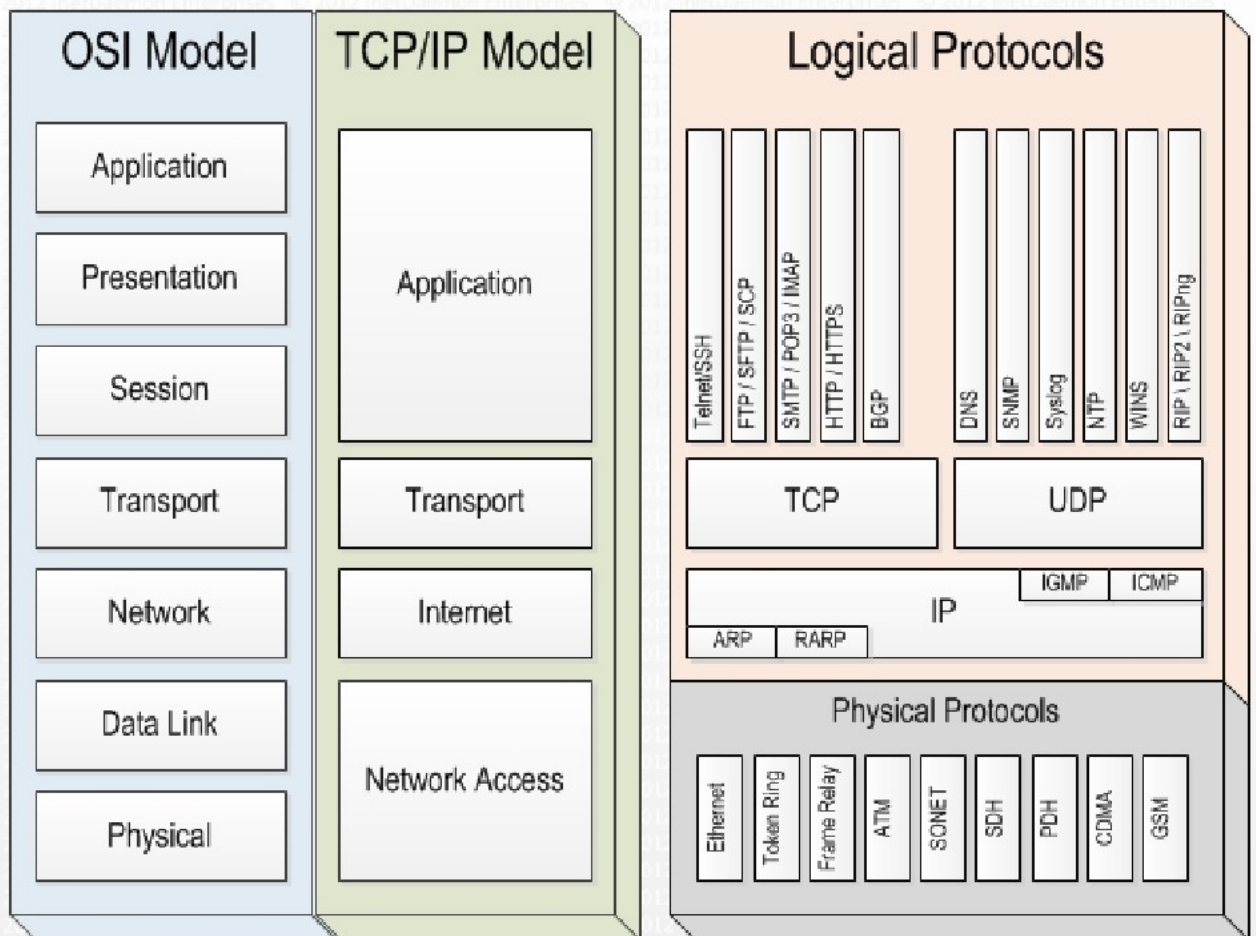
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Application layer's PDU is data.

For your exam you should know below information about TCP/IP model:
Network models

NETWORK MODELS



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

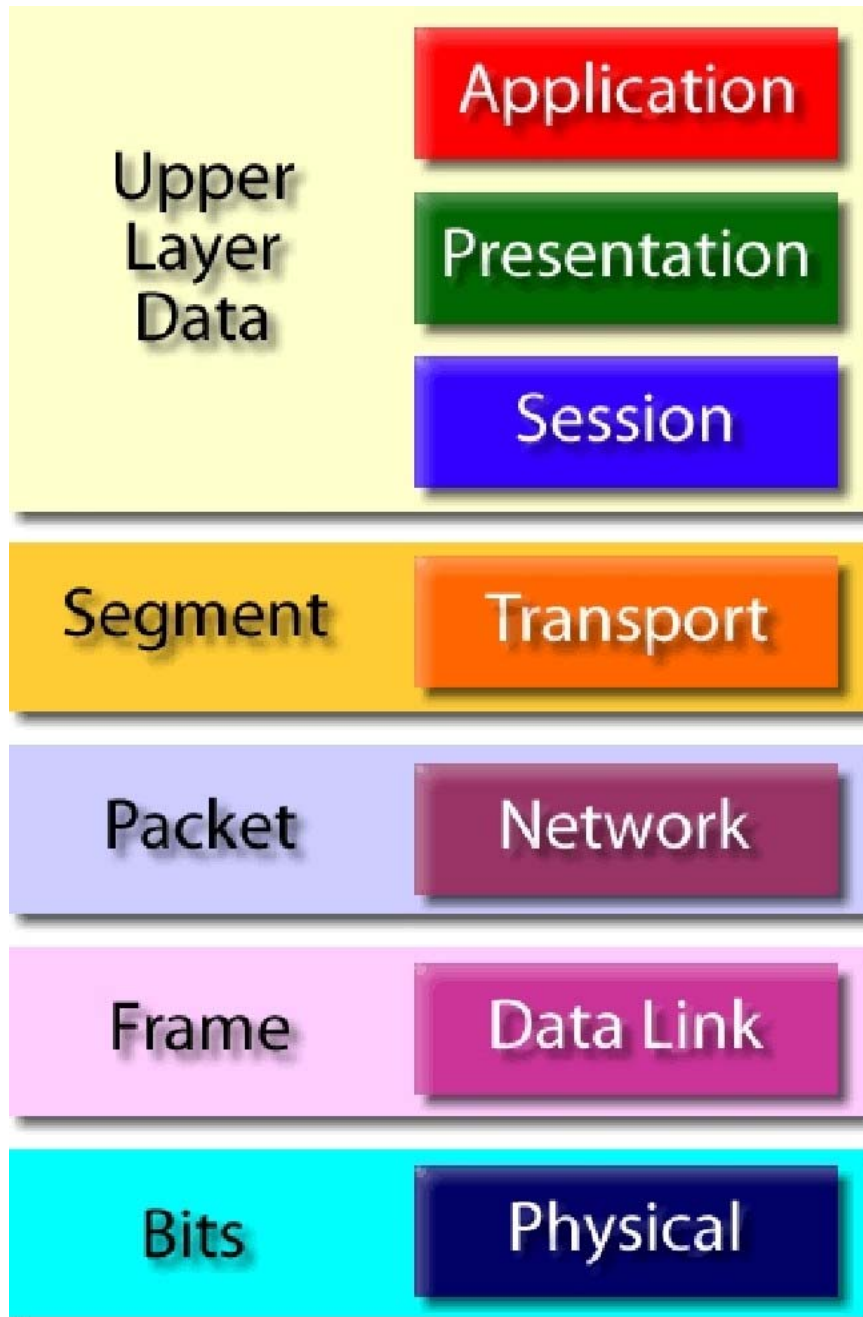
The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/

Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

Segment Transport layer PDU
Packet Network interface layer PDU
Frame/bit LAN or WAN interface layer PDU
CISA review manual 2014 page number 272

QUESTION 453

Which of the following is protocol data unit (PDU) of transport layer in TCP/IP model?

- A. Data
- B. Segment
- C. Packet
- D. Frame

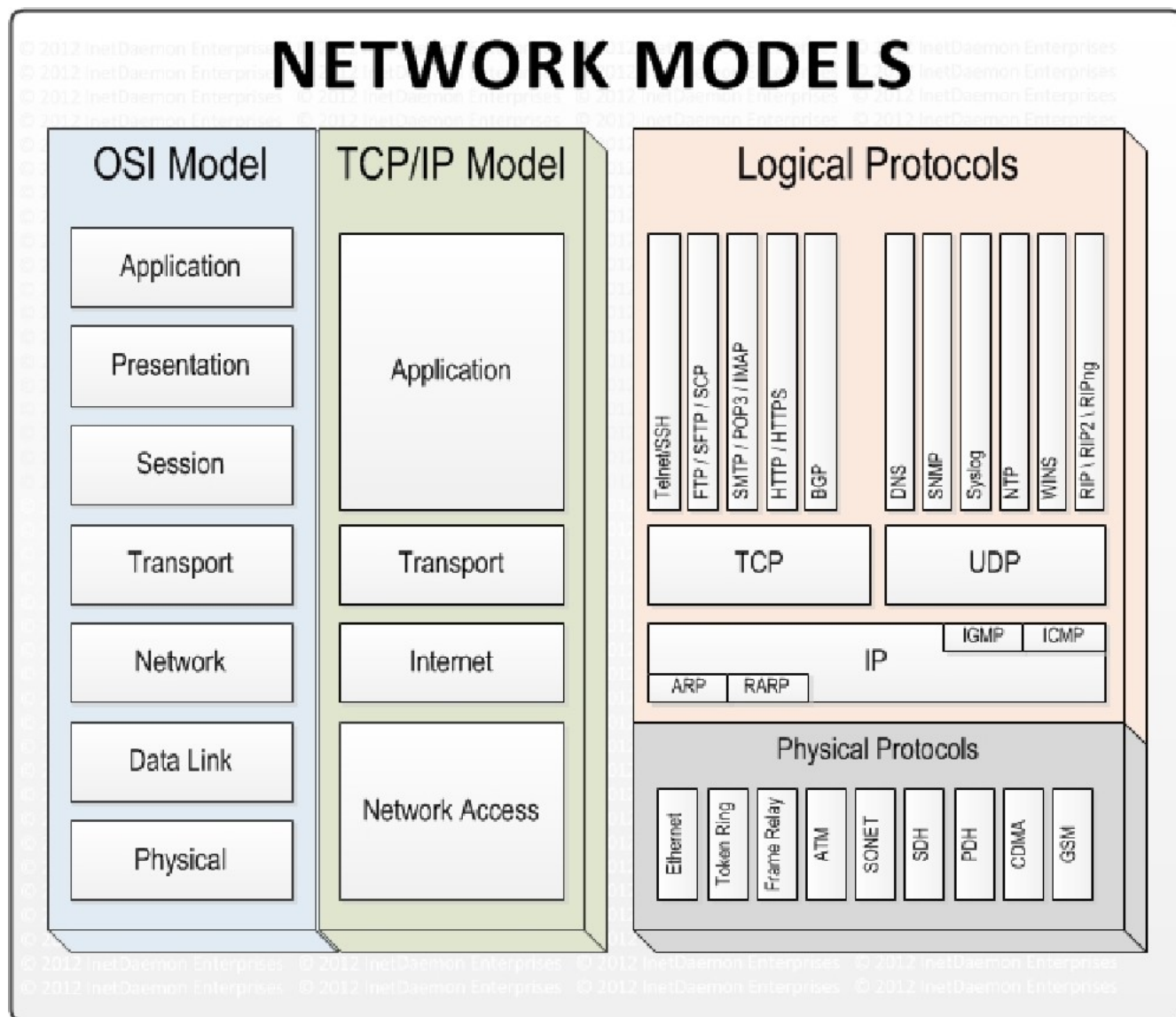
Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support For your exam you should know below information about TCP/IP model:

Network models



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

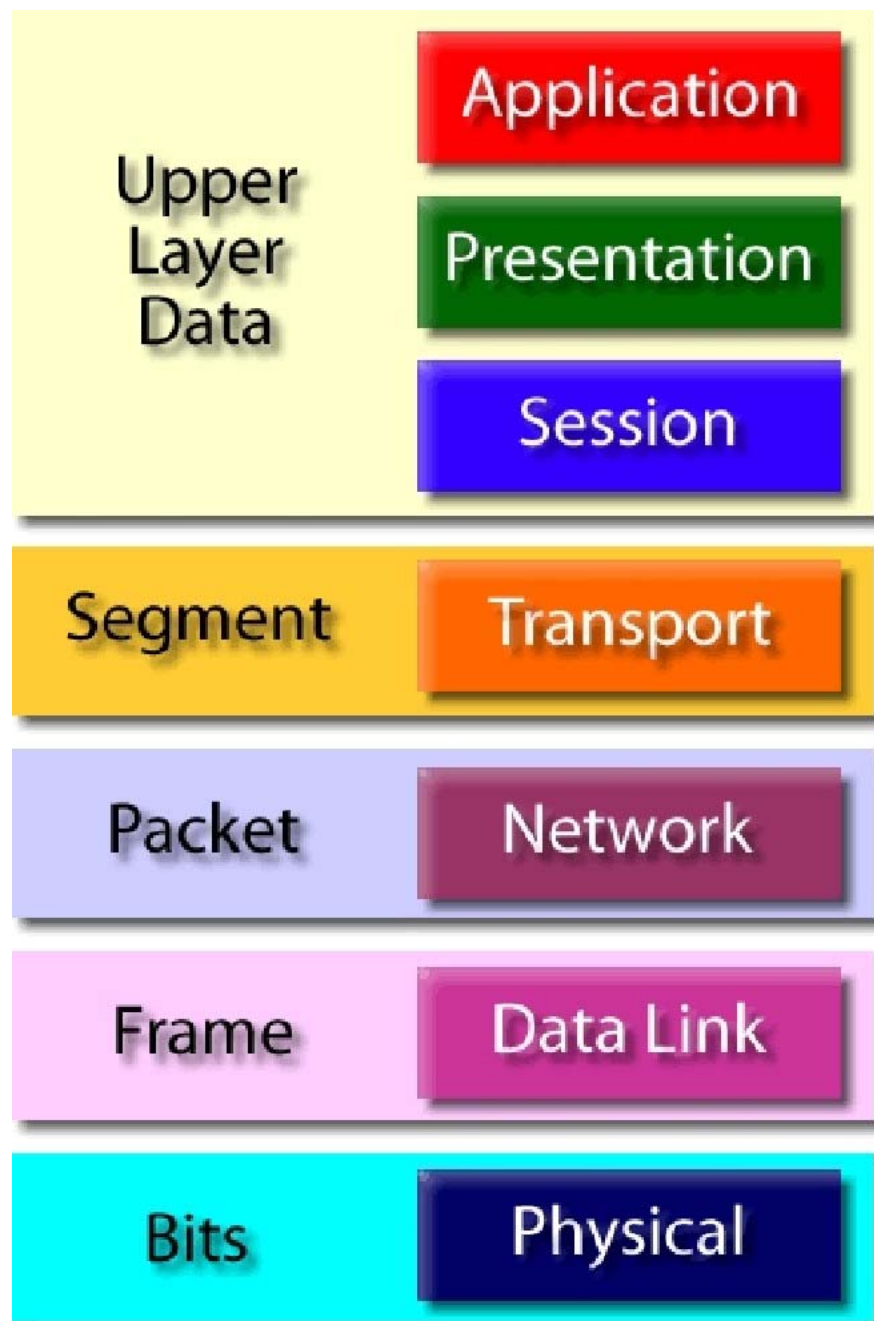
Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/ Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

Data Application layer PDU
Packet Network interface layer PDU
Frame/bit LAN or WAN interface layer PDU
CISA review manual 2014 page number 272

QUESTION 454

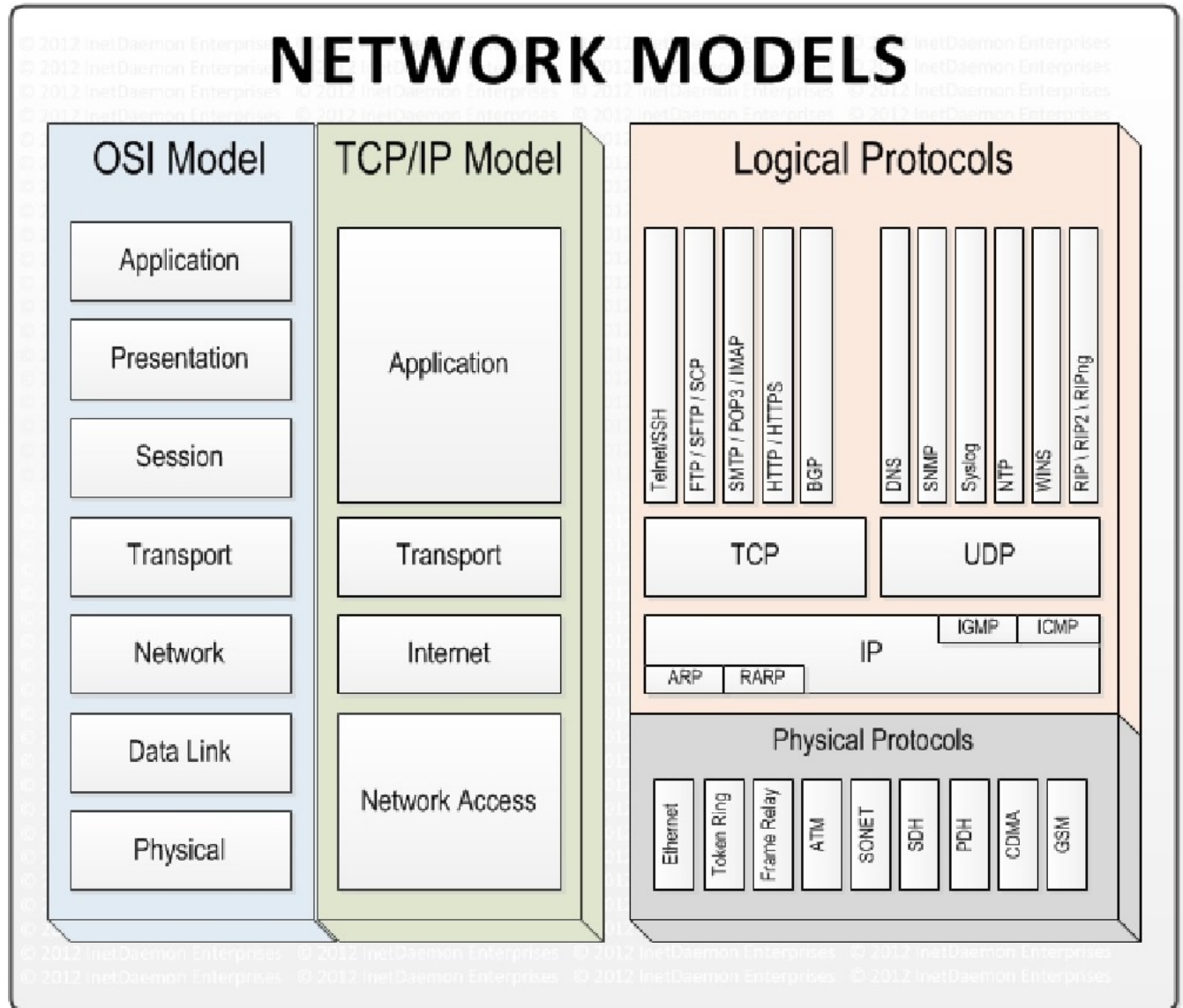
Which of the following is protocol data unit (PDU) of network interface layer in TCP/IP model?

- A. Data
- B. Segment
- C. Packet
- D. Frame

Correct Answer: C
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support For your exam you should know below information about TCP/IP model:
 Network models



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It

is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

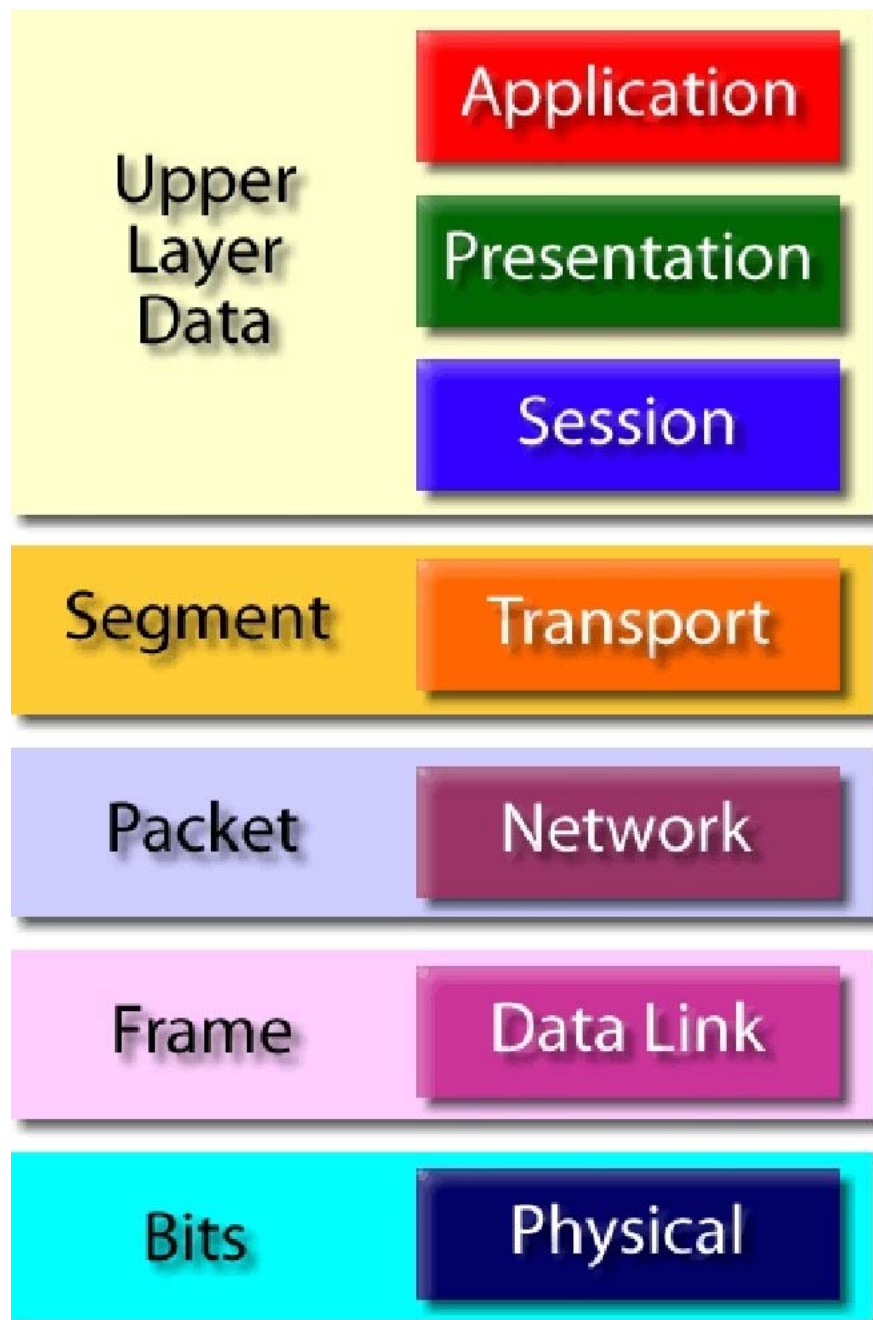
Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/ Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

Data Application layer PDU
Segment Transport layer PDU

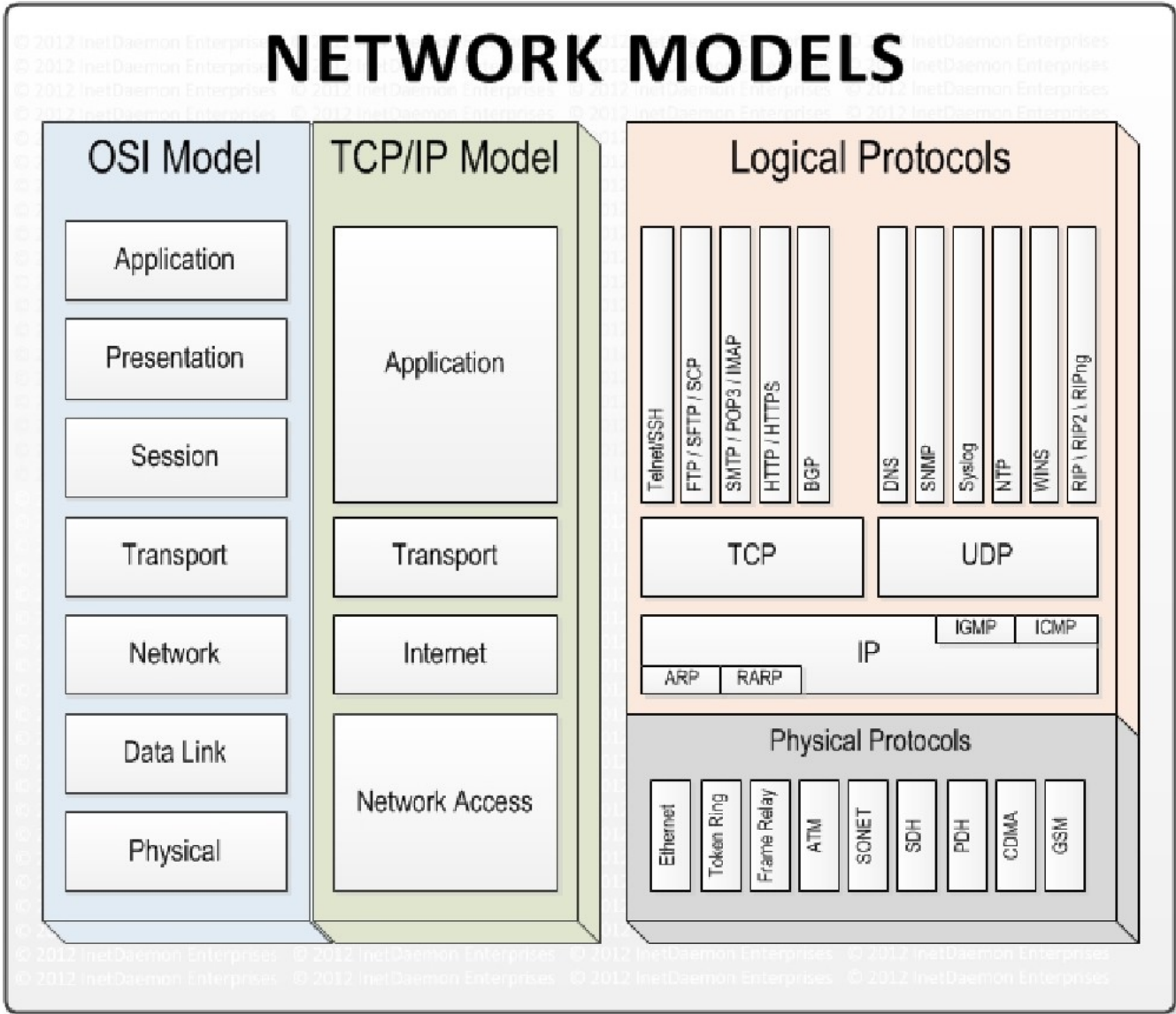
QUESTION 455

Which of the following is protocol data unit (PDU) of data at LAN or WAN interface layer in TCP/IP model?

- A. Data
- B. Segment
- C. Packet
- D. Frame and bits

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support For your exam you should know below information about TCP/IP model:
Network Models



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

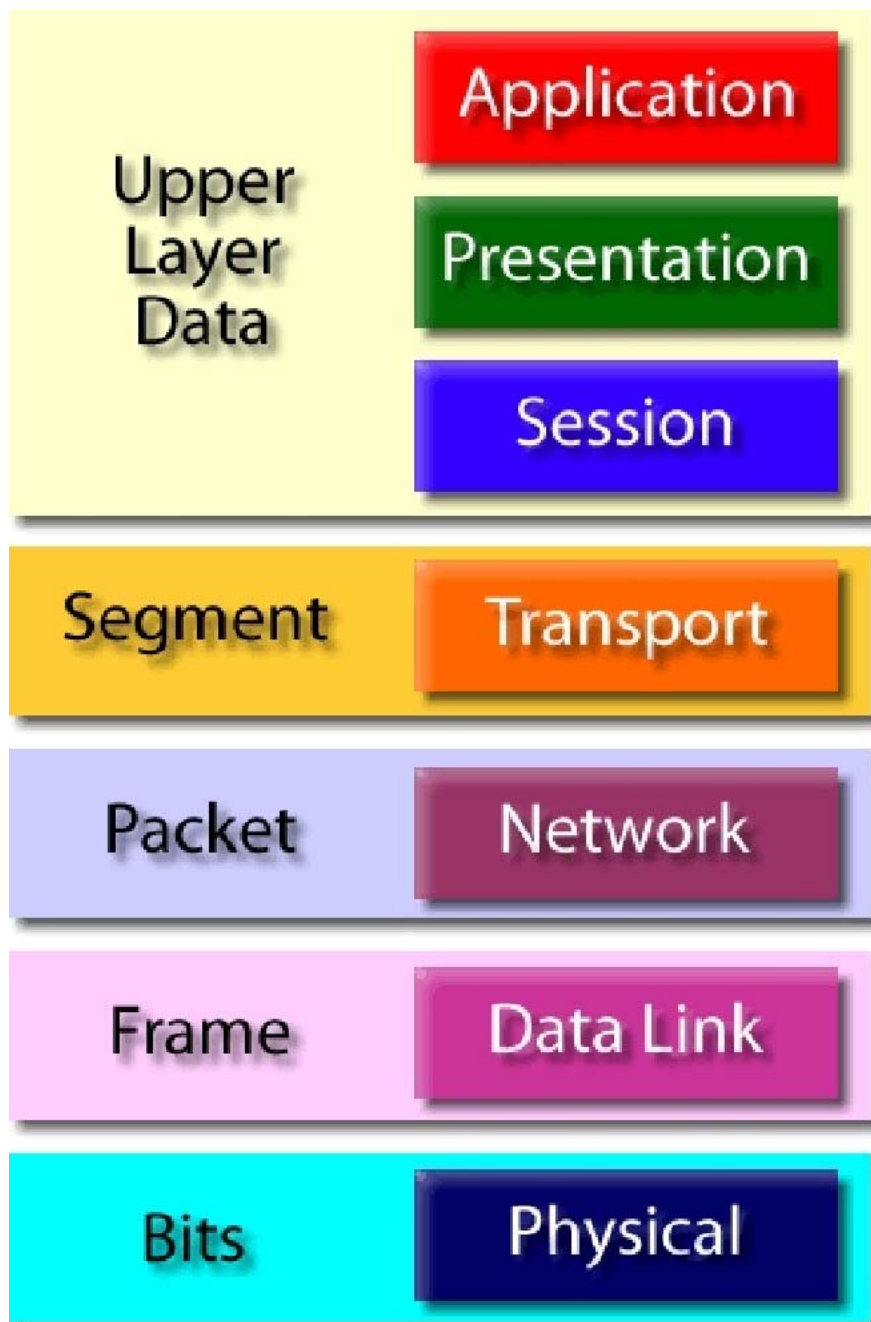
Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/ Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

Data Application layer data PDU
Segment Transport layer data PDU
Packet Network interface layer data PDU
CISA review manual 2014 page number 272

QUESTION 456

Which of the following INCORRECTLY describes the layer function of the Application Layer within the TCP/IP model?

- A. Provides user interface
- B. Perform data processing such as encryption, encoding, etc
- C. Provides reliable delivery
- D. Keeps separate the data of different applications

Correct Answer: C

Explanation

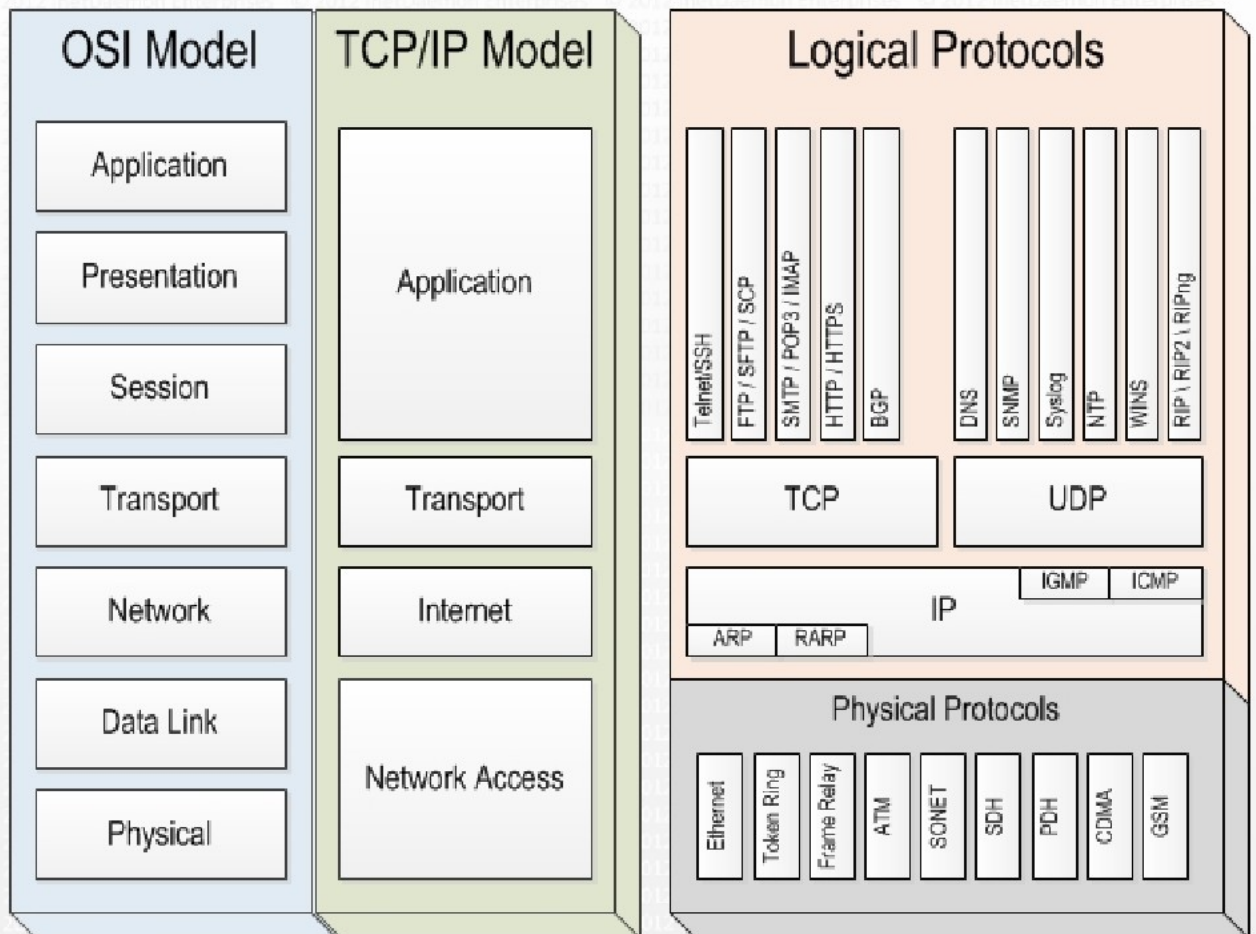
Explanation/Reference:

Section: Information System Operations, Maintenance and Support The word INCORRECTLY keyword is used in the question.

You need to find out the service or functionality which is not performed by application layer of a TCP/IP model. The reliable or unreliable delivery of a message is the functionality of transport layer of a TCP/IP model.

For your exam you should know below information about TCP/IP model:
Network Models

NETWORK MODELS



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

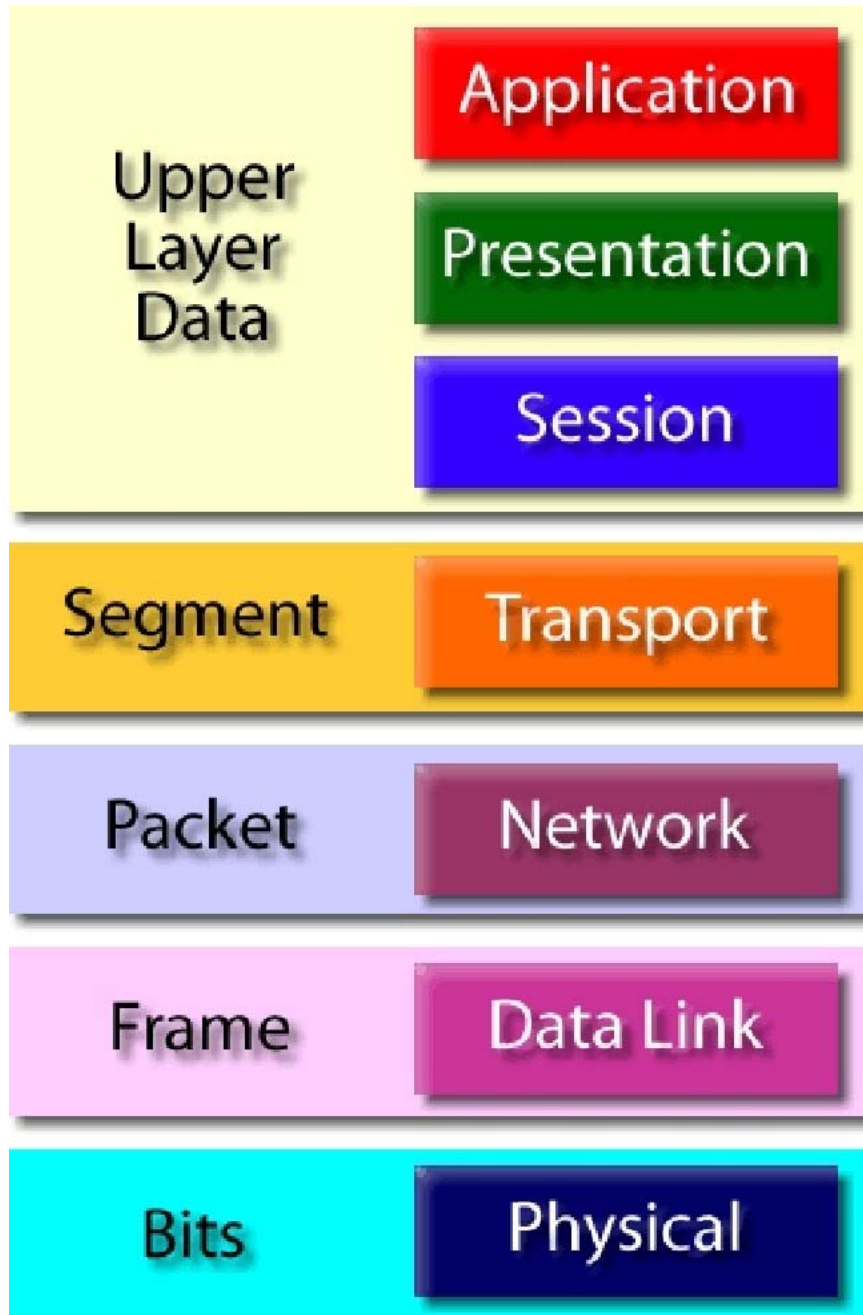
The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/

Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of

time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

The other options correctly describe functionalities of application layer in TCP/IP model.
CISA review manual 2014 page number 272

QUESTION 457

Which of the following INCORRECTLY describes the layer functions of the LAN or WAN Layer of the TCP/IP model?

- A. Combines packets into bytes and bytes into frame
- B. Provides logical addressing which routers use for path determination
- C. Provide address to media using MAC address
- D. Performs only error detection

Correct Answer: B

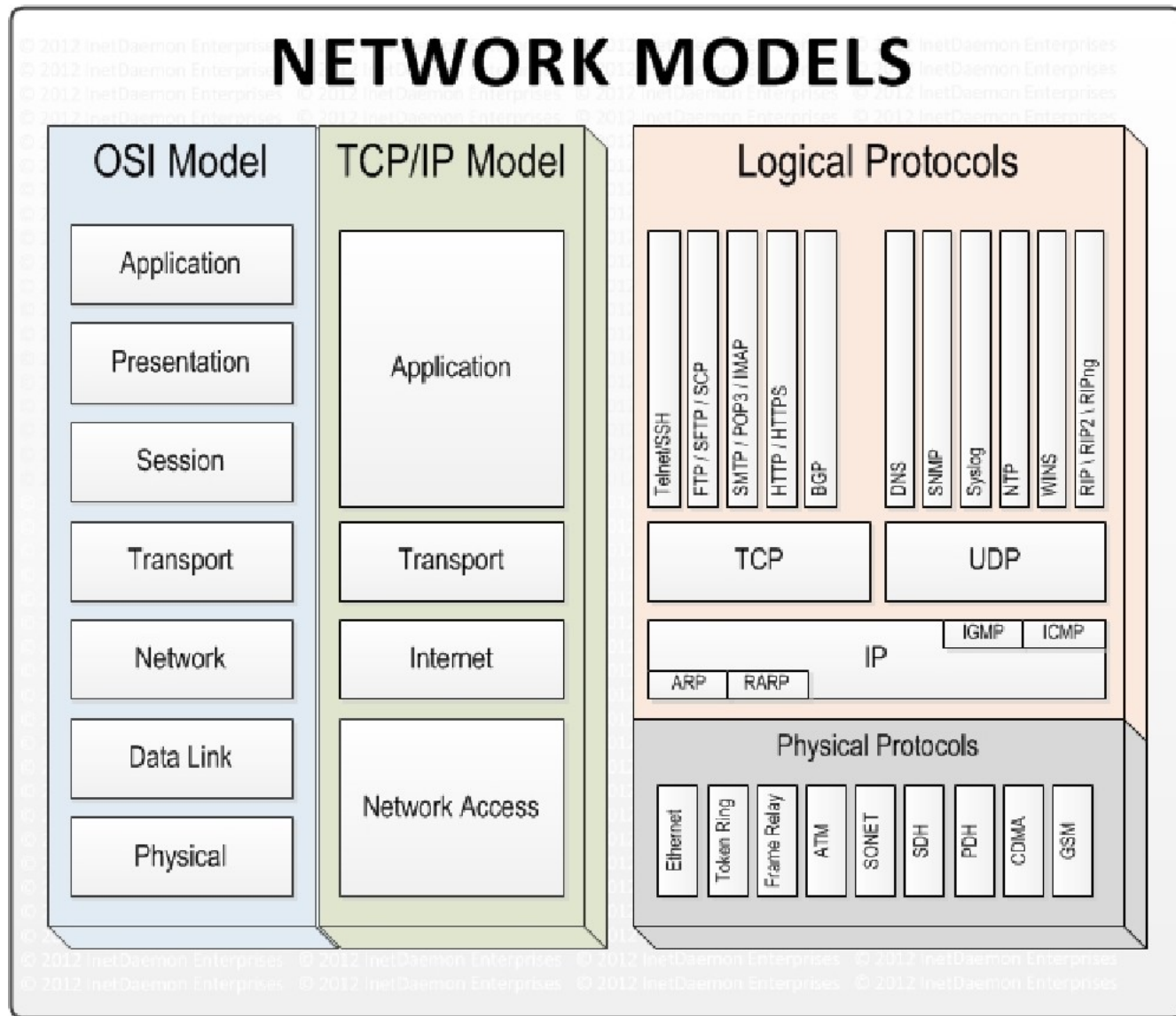
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The word INCORRECTLY is the keyword used in the question. You need to find out the functionality that is not performed by LAN or WAN layer in TCP/IP model.

The Network layer of a TCP/IP model provides logical addressing which routers use for path determination. For your exam you should know below information about TCP/IP model:

Network Models



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

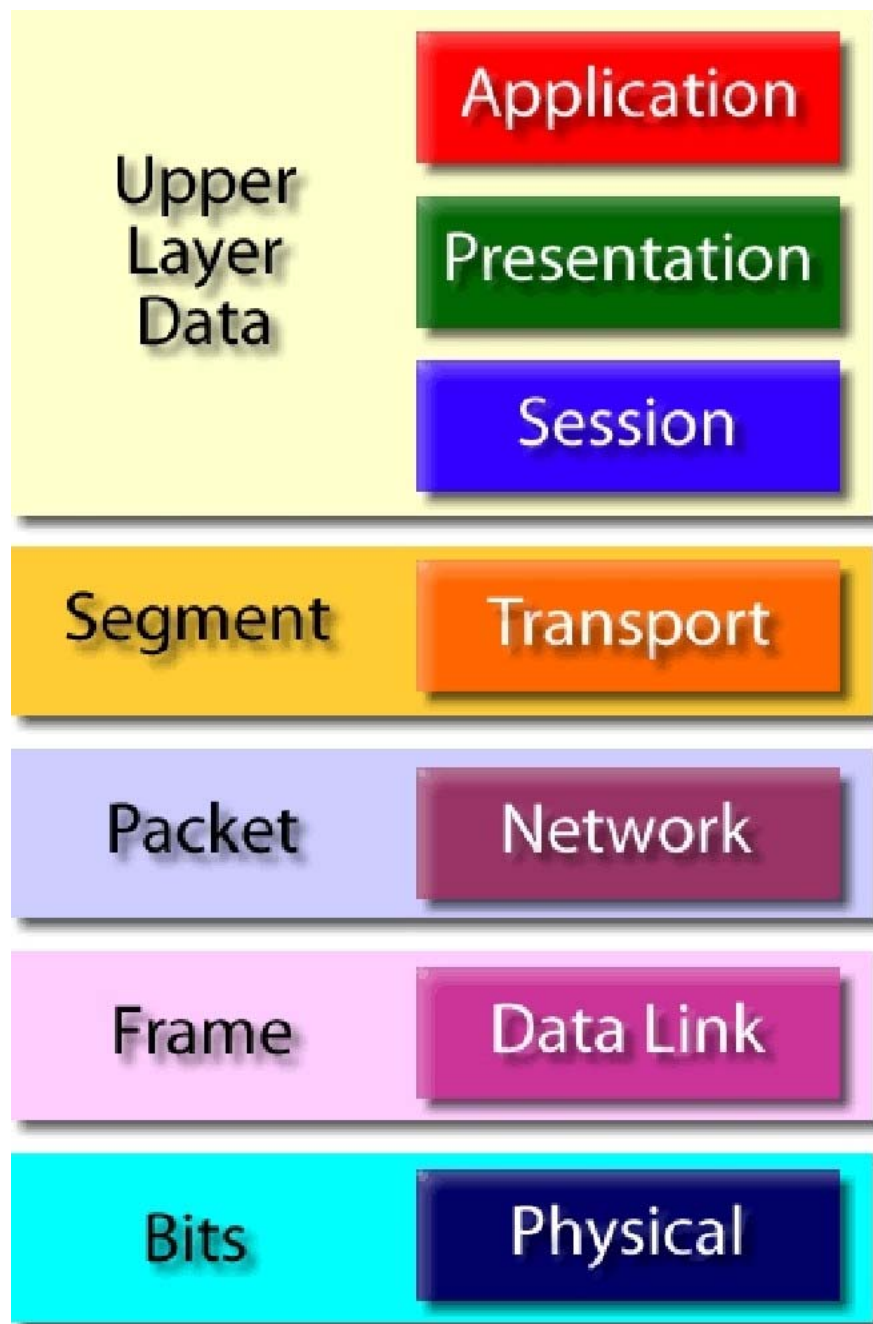
Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/ Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

The other options correctly describe functionalities of application layer in TCP/IP model.
CISA review manual 2014 page number 272

QUESTION 458

Which of the following functionality is NOT performed by the application layer of a TCP/IP model?

- A. Print service, application services
- B. Data encryption and compression
- C. Dialog management
- D. End-to-end connection

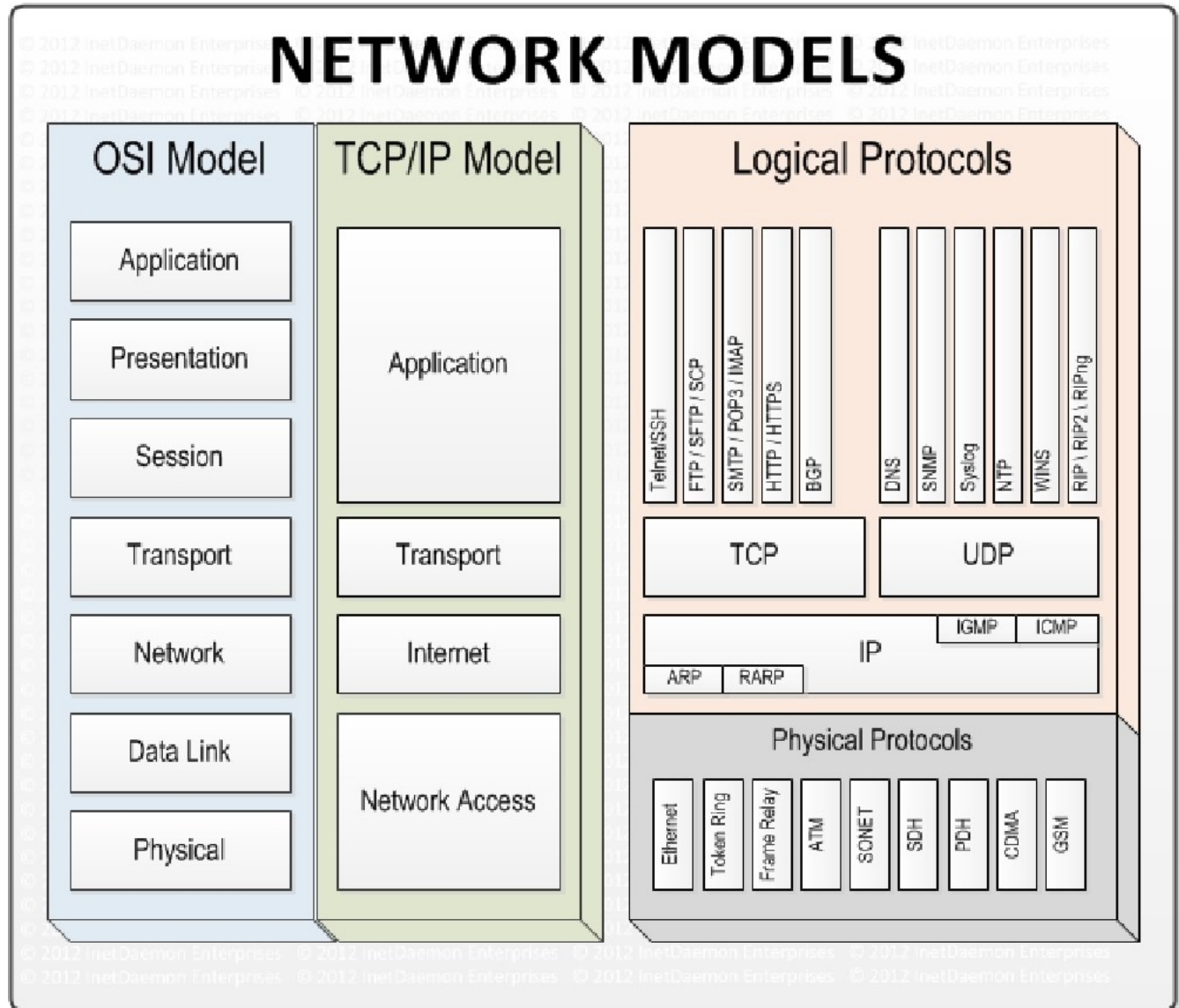
Correct Answer: D
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The word NOT is the keyword used in the question. You need to find out a functionality which is not performed by application layer of a TCP/IP model.

End-to-end connection is the Transport layer functionality in TCP/IP model.

For your exam you should know below information about TCP/IP model:
 Network Models



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to

forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

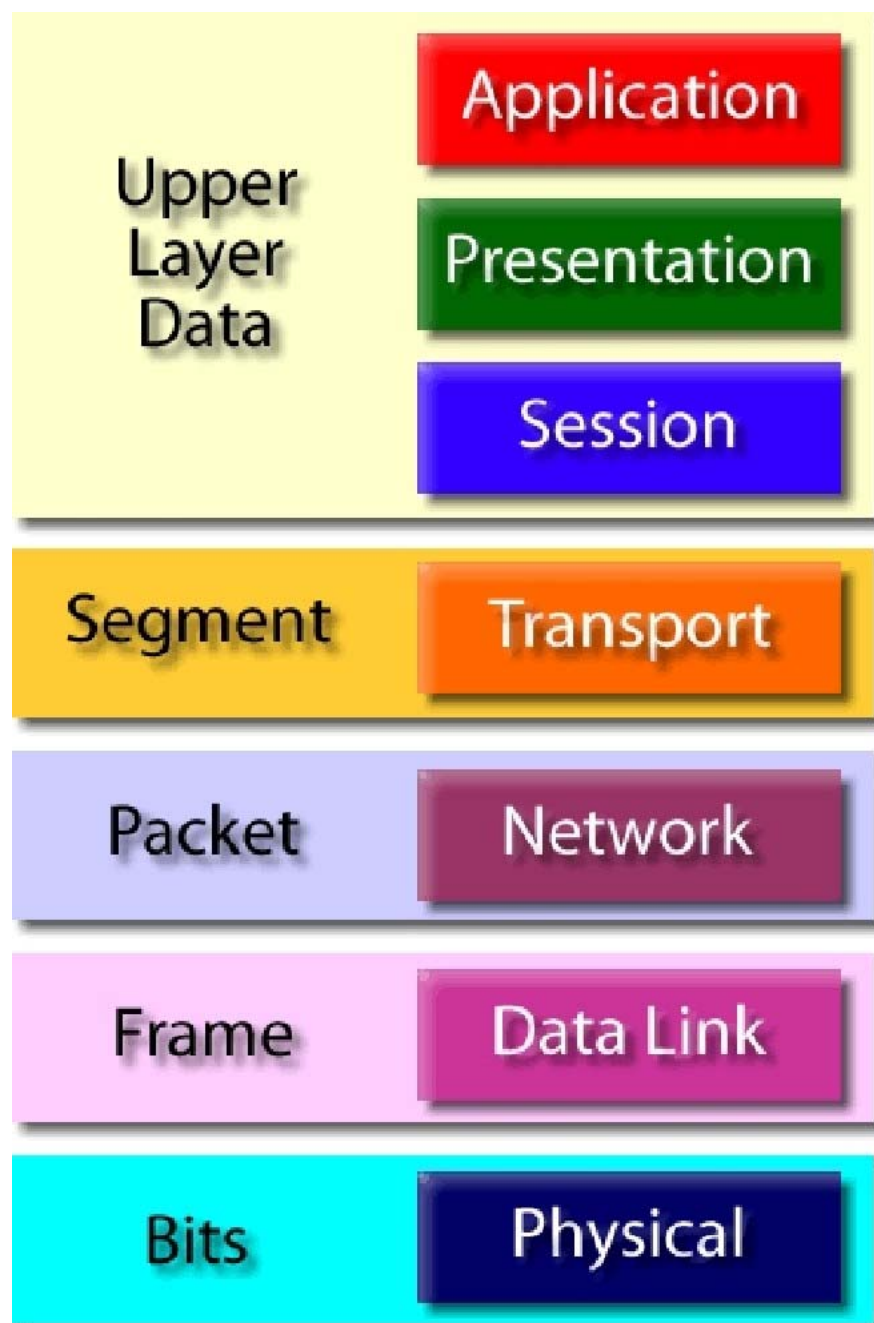
Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/ Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

The other functionalities described in the options are performed by application layer in TCP/IP model.
CISA review manual 2014 page number 272

QUESTION 459

Which of the following is the INCORRECT "layer - protocol" mapping within the TCP/IP model?

- A. Application layer NFS
- B. Transport layer TCP
- C. Network layer UDP
- D. LAN or WAN interface layer point-to-point protocol

Correct Answer: C

Explanation

Explanation/Reference:

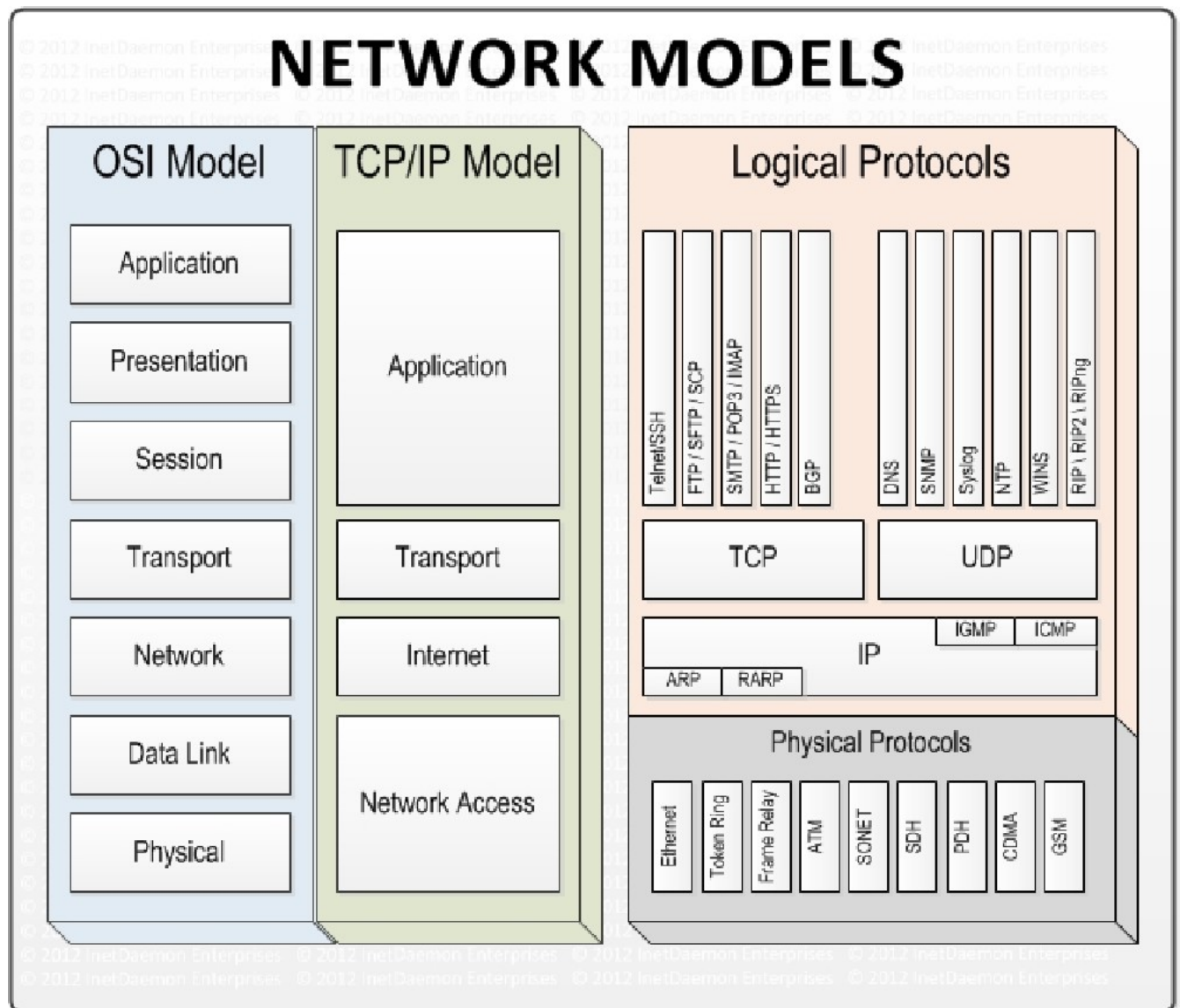
Section: Information System Operations, Maintenance and Support The word INCORRECT is the keyword used in the question.

You need to find out invalid layer-protocol mapping.

The UDP protocol works at Transport layer of a TCP/IP model.

For your exam you should know below information about TCP/IP model:

Network Models



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of

Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

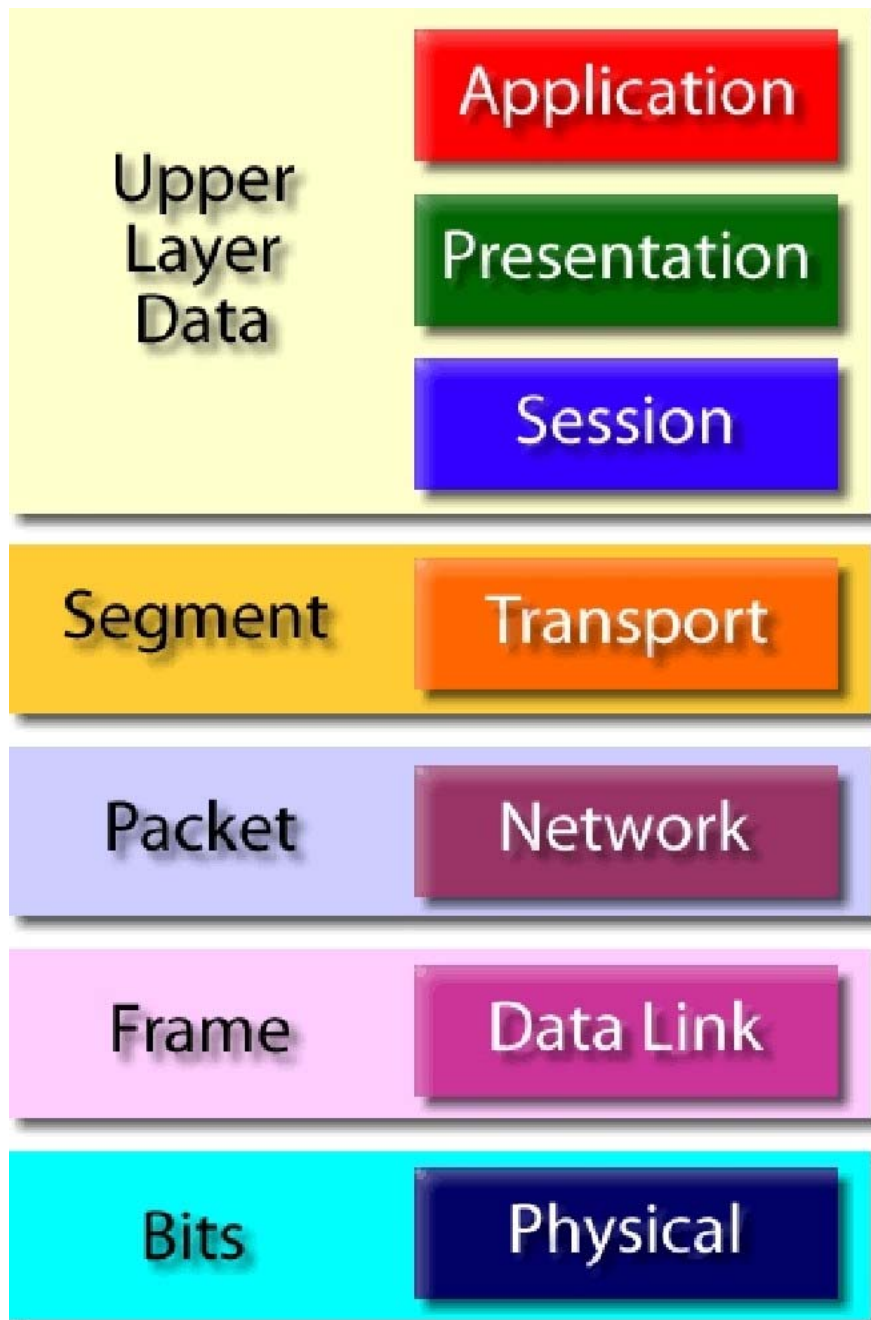
Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/ Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

The other options correctly describe layer-protocol mapping in TCP/IP protocol.
CISA review manual 2014 page number 272

QUESTION 460

Which of the following is the INCORRECT "layer - protocol data unit (PDU)" mapping within the TCP/IP model?

- A. Application layer Data
- B. Transport layer Segment
- C. Network layer Frame
- D. Physical layer bits

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The word INCORRECT is the keyword used in the question. You need to find out incorrect layer-protocol mapping from give options.

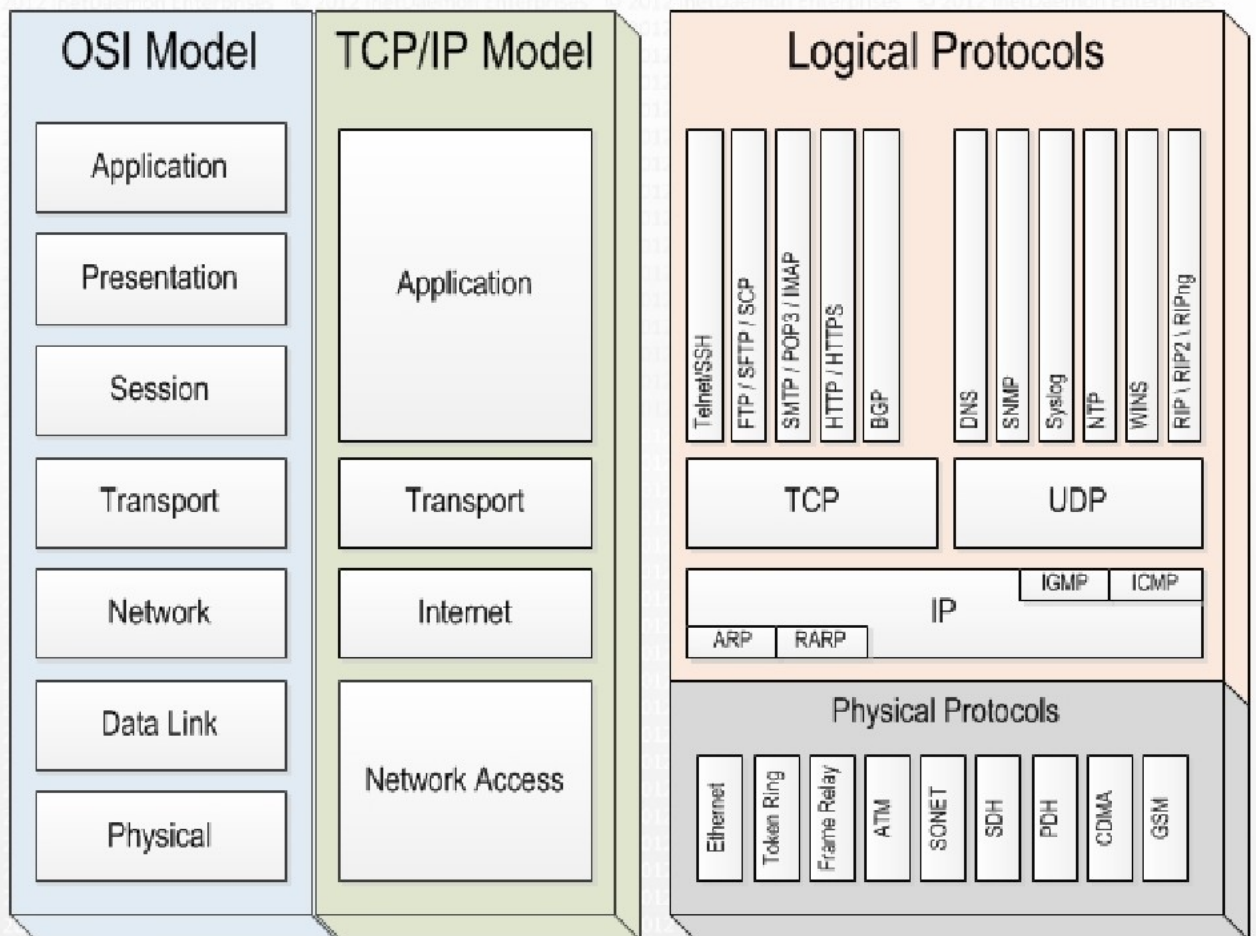
The correct mapping is Network layer Packet.

The LAN or WAN interface layer creates frame.

For your exam you should know below information about TCP/IP model:

Network Models

NETWORK MODELS



Layer 4. Application Layer

Application layer is the top most layer of four layer TCP/IP model. Application layer is present on the top of the Transport layer. Application layer defines TCP/IP application protocols and how host programs interface with Transport layer services to use the network.

Application layer includes all the higher-level protocols like DNS (Domain Naming System), HTTP (Hypertext Transfer Protocol), Telnet, SSH, FTP (File Transfer Protocol), TFTP (Trivial File Transfer Protocol), SNMP (Simple Network Management Protocol), SMTP (Simple Mail Transfer Protocol), DHCP (Dynamic Host Configuration Protocol), X Windows, RDP (Remote Desktop Protocol) etc.

Layer 3. Transport Layer

Transport Layer is the third layer of the four layer TCP/IP model. The position of the Transport layer is between Application layer and Internet layer. The purpose of Transport layer is to permit devices on the source and destination hosts to carry on a conversation. Transport layer defines the level of service and status of the connection used when transporting data.

The main protocols included at Transport layer are TCP (Transmission Control Protocol) and UDP (User Datagram Protocol).

Layer 2. Internet Layer

Internet Layer is the second layer of the four layer TCP/IP model. The position of Internet layer is between Network Access Layer and Transport layer. Internet layer pack data into data packets known as IP datagram's, which contain source and destination address (logical address or IP address) information that is used to forward the datagram's between hosts and across networks. The Internet layer is also responsible for routing of IP datagram's.

Packet switching network depends upon a connectionless internetwork layer. This layer is known as Internet layer. Its job is to allow hosts to insert packets into any network and have them to deliver independently to the destination. At the destination side data packets may appear in a different order than they were sent. It is the job of the higher layers to rearrange them in order to deliver them to proper network applications operating at the Application layer.

The main protocols included at Internet layer are IP (Internet Protocol), ICMP (Internet Control Message Protocol), ARP (Address Resolution Protocol), RARP (Reverse Address Resolution Protocol) and IGMP (Internet Group Management Protocol).

Layer 1. Network Access Layer

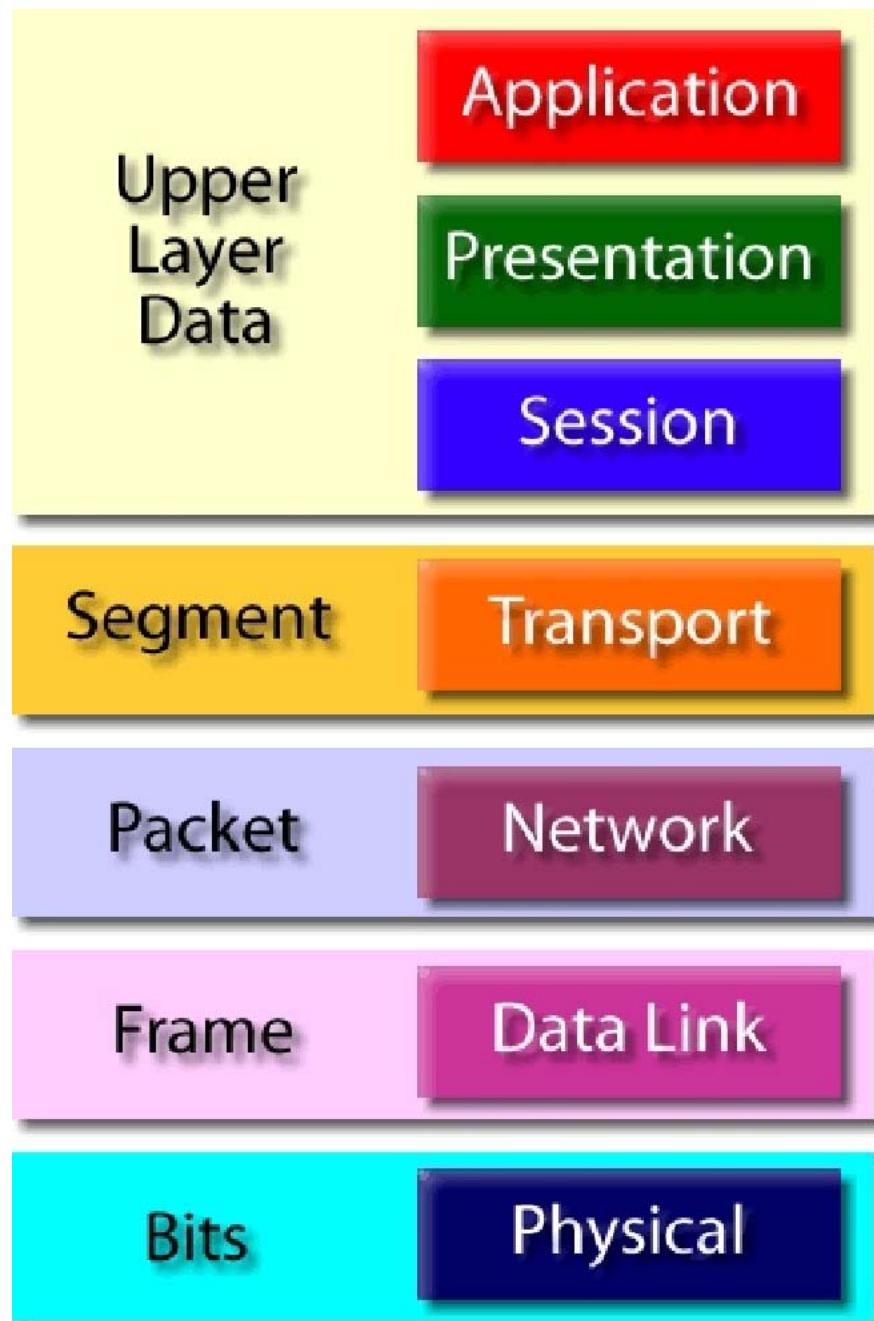
Network Access Layer is the first layer of the four layer TCP/IP model. Network Access Layer defines details of how data is physically sent through the network, including how bits are electrically or optically signaled by hardware devices that interface directly with a network medium, such as coaxial cable, optical fiber, or twisted pair copper wire.

The protocols included in Network Access Layer are Ethernet, Token Ring, FDDI, X.25, Frame Relay etc.

The most popular LAN architecture among those listed above is Ethernet. Ethernet uses an Access Method called CSMA/CD (Carrier Sense Multiple Access/ Collision Detection) to access the media, when Ethernet operates in a shared media. An Access Method determines how a host will place data on the medium.

IN CSMA/CD Access Method, every host has equal access to the medium and can place data on the wire when the wire is free from network traffic. When a host wants to place data on the wire, it will check the wire to find whether another host is already using the medium. If there is traffic already in the medium, the host will wait and if there is no traffic, it will place the data in the medium. But, if two systems place data on the medium at the same instance, they will collide with each other, destroying the data. If the data is destroyed during transmission, the data will need to be retransmitted. After collision, each host will wait for a small interval of time and again the data will be retransmitted.

Protocol Data Unit (PDU):



The following answers are incorrect:

The other options correctly describe layer-PDU mapping in TCP/IP protocol.
CISA review manual 2014 page number 272

QUESTION 461

Which of the following protocol is used for electronic mail service?

- A. DNS
- B. FTP
- C. SSH
- D. SMTP

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support SMTP (Simple Mail Transfer Protocol) is a TCP/IP protocol used in sending and receiving e-mail. However, since it is limited in its ability to queue messages at the receiving end, it is usually used with one of two other protocols, POP3 or IMAP, that let the user save messages in a server mailbox and download them periodically from the server. In other words, users typically use a program that uses SMTP for sending e-mail and either POP3 or IMAP for receiving e-mail. On Unix-based systems, send mail is the most widely-used SMTP server for e-mail. A commercial package, Send mail, includes a POP3 server. Microsoft Exchange includes an SMTP server and can also be set up to include POP3 support.

For your exam you should know below information general Internet terminology:

Network access point -Internet service providers access internet using net access point. A Network Access Point (NAP) was a public network exchange facility where Internet service providers (ISPs) connected with one another in peering arrangements. The NAPs were a key component in the transition from the 1990s NSFNET era (when many networks were government sponsored and commercial traffic was prohibited) to the commercial Internet providers of today. They were often points of considerable Internet congestion.

Internet Service Provider (ISP) - An Internet service provider (ISP) is an organization that provides services for accessing, using, or participating in the Internet. Internet service providers may be organized in various forms, such as commercial, community-owned, non-profit, or otherwise privately owned. Internet services typically provided by ISPs include Internet access, Internet transit, domain name registration, web hosting, co-location.

Telnet or Remote Terminal Control Protocol -A terminal emulation program for TCP/IP networks such as the Internet. The Telnet program runs on your computer and connects your PC to a server on the network. You can then enter commands through the Telnet program and they will be executed as if you were entering them directly on the server console. This enables you to control the server and communicate with other servers on the network. To start a Telnet session, you must log in to a server by entering a valid username and password.

Telnet is a common way to remotely control Web servers.

Internet Link- Internet link is a connection between Internet users and the Internet service provider.

Secure Shell or Secure Socket Shell (SSH) - Secure Shell (SSH), sometimes known as Secure Socket Shell, is a UNIX-based command interface and protocol for securely getting access to a remote computer. It is widely used by network administrators to control Web and other kinds of servers remotely. SSH is actually a suite of three utilities - slogin, sash, and scp - that are secure versions of the earlier UNIX utilities, rlogin, rash, and rap. SSH commands are encrypted and secure in several ways. Both ends of the client/server connection are authenticated using a digital certificate, and passwords are protected by being encrypted.

Domain Name System (DNS) - The Domain Name System (DNS) is a hierarchical distributed naming system for computers, services, or any resource connected to the Internet or a private network. It associates information from domain names with each of the assigned entities. Most prominently, it translates easily memorized domain names to the numerical IP addresses needed for locating computer services and devices worldwide. The Domain Name System is an essential component of the functionality of the Internet. This article presents a functional description of the Domain Name System.

File Transfer Protocol (FTP) - The File Transfer Protocol or FTP is a client/server application that is used to move files from one system to another. The client connects to the FTP server, authenticates and is given access that the server is configured to permit. FTP servers can also be configured to allow anonymous access by logging in with an email address but no password. Once connected, the client may move around between directories with commands available

Simple Mail Transport Protocol (SMTP) - SMTP (Simple Mail Transfer Protocol) is a TCP/IP protocol used in sending and receiving e-mail. However, since it is limited in its ability to queue messages at the receiving end, it is usually used with one of two other protocols, POP3 or IMAP, that let the user save messages in a server mailbox and download them periodically from the server. In other words, users typically use a program that uses SMTP for sending e-mail and either POP3 or IMAP for receiving e-mail. On Unix-based systems, send mail is the most widely-used SMTP server for e-mail. A commercial package, Send mail, includes a POP3 server. Microsoft Exchange includes an SMTP server and can also be set up to include POP3 support.

The following answers are incorrect:

DNS - The Domain Name System (DNS) is a hierarchical distributed naming system for computers, services, or any resource connected to the Internet or a private network. It associates information from domain names with each of the assigned entities. Most prominently, it translates easily memorized domain names to the numerical IP addresses needed for locating computer services and devices worldwide. The Domain Name System is an essential component of the functionality of the Internet. This article presents a functional description of the Domain Name System.

FTP - The File Transfer Protocol or FTP is a client/server application that is used to move files from one system to another. The client connects to the FTP server, authenticates and is given access that the server is configured to permit. FTP servers can also be configured to allow anonymous access by logging in with an email address but no password. Once connected, the client may move around between directories with commands available

SSH - Secure Shell (SSH), sometimes known as Secure Socket Shell, is a UNIX-based command interface and protocol for securely getting access to a remote computer. It is widely used by network administrators to control Web and other kinds of servers remotely. SSH is actually a suite of three utilities - slogin, sash, and scp - that are secure versions of the earlier UNIX utilities, rlogin, rash, and rap. SSH commands are encrypted and secure in several ways. Both ends of the client/server connection are authenticated using a digital certificate, and passwords are protected by being encrypted.

CISA review manual 2014 page number 273 and 274

QUESTION 462

Which of the following service is a distributed database that translate host name to IP address to IP address to host name?

- A. DNS
- B. FTP
- C. SSH
- D. SMTP

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The Domain Name System (DNS) is a hierarchical distributed naming system for computers, services, or any resource connected to the Internet or a private network. It associates information from domain names with each of the assigned entities. Most prominently, it translates easily memorized domain names to the numerical

IP addresses needed for locating computer services and devices worldwide. The Domain Name System is an essential component of the functionality of the Internet. This article presents a functional description of the Domain Name System.

For your exam you should know below information general Internet terminology:

Network access point -Internet service providers access internet using net access point. A Network Access Point (NAP) was a public network exchange facility where Internet service providers (ISPs) connected with one another in peering arrangements. The NAPs were a key component in the transition from the 1990s NSFNET era (when many networks were government sponsored and commercial traffic was prohibited) to the commercial Internet providers of today. They were often points of considerable Internet congestion.

Internet Service Provider (ISP) - An Internet service provider (ISP) is an organization that provides services for accessing, using, or participating in the Internet. Internet service providers may be organized in various forms, such as commercial, community-owned, non-profit, or otherwise privately owned. Internet services typically provided by ISPs include Internet access, Internet transit, domain name registration, web hosting, co-location.

Telnet or Remote Terminal Control Protocol -A terminal emulation program for TCP/IP networks such as the Internet. The Telnet program runs on your computer and connects your PC to a server on the network. You can then enter commands through the Telnet program and they will be executed as if you were entering

them directly on the server console. This enables you to control the server and communicate with other servers on the network. To start a Telnet session, you must log in to a server by entering a valid username and password. Telnet is a common way to remotely control Web servers.

Internet Link- Internet link is a connection between Internet users and the Internet service provider.

Secure Shell or Secure Socket Shell (SSH) - Secure Shell (SSH), sometimes known as Secure Socket Shell, is a UNIX-based command interface and protocol for securely getting access to a remote computer. It is widely used by network administrators to control Web and other kinds of servers remotely. SSH is actually a suite of three utilities - slogin, sash, and scp - that are secure versions of the earlier UNIX utilities, rlogin, rsh, and rcp. SSH commands are encrypted and secure in several ways. Both ends of the client/server connection are authenticated using a digital certificate, and passwords are protected by being encrypted.

Domain Name System (DNS) - The Domain Name System (DNS) is a hierarchical distributed naming system for computers, services, or any resource connected to the Internet or a private network. It associates information from domain names with each of the assigned entities. Most prominently, it translates easily memorized domain names to the numerical IP addresses needed for locating computer services and devices worldwide. The Domain Name System is an essential component of the functionality of the Internet. This article presents a functional description of the Domain Name System.

File Transfer Protocol (FTP) - The File Transfer Protocol or FTP is a client/server application that is used to move files from one system to another. The client connects to the FTP server, authenticates and is given access that the server is configured to permit. FTP servers can also be configured to allow anonymous access by logging in with an email address but no password. Once connected, the client may move around between directories with commands available

Simple Mail Transport Protocol (SMTP) - SMTP (Simple Mail Transfer Protocol) is a TCP/IP protocol used in sending and receiving e-mail. However, since it is limited in its ability to queue messages at the receiving end, it is usually used with one of two other protocols, POP3 or IMAP, that let the user save messages in a server mailbox and download them periodically from the server. In other words, users typically use a program that uses SMTP for sending e-mail and either POP3 or IMAP for receiving e-mail. On Unix-based systems, sendmail is the most widely-used SMTP server for e-mail. A commercial package, Sendmail, includes a POP3 server. Microsoft Exchange includes an SMTP server and can also be set up to include POP3 support.

The following answers are incorrect:

SMTP - Simple Mail Transport Protocol (SMTP) - SMTP (Simple Mail Transfer Protocol) is a TCP/IP protocol used in sending and receiving e-mail. However, since it is limited in its ability to queue messages at the receiving end, it is usually used with one of two other protocols, POP3 or IMAP, that let the user save messages in a server mailbox and download them periodically from the server. In other words, users typically

use a program that uses SMTP for sending e-mail and either POP3 or IMAP for receiving e-mail. On Unix-based systems, sendmail is the most widely-used SMTP server for e-mail. A commercial package, Sendmail, includes a POP3 server. Microsoft Exchange includes an SMTP server and can also be set up to include POP3 support.

FTP - The File Transfer Protocol or FTP is a client/server application that is used to move files from one system to another. The client connects to the FTP server, authenticates and is given access that the server is configured to permit. FTP servers can also be configured to allow anonymous access by logging in with an email address but no password. Once connected, the client may move around between directories with commands available

SSH - Secure Shell (SSH), sometimes known as Secure Socket Shell, is a UNIX-based command interface and protocol for securely getting access to a remote computer. It is widely used by network administrators to control Web and other kinds of servers remotely. SSH is actually a suite of three utilities - slogin, sash, and scp - that are secure versions of the earlier UNIX utilities, rlogin, rsh, and rcp. SSH commands are encrypted and secure in several ways. Both ends of the client/server connection are authenticated using a digital certificate, and passwords are protected by being encrypted.
CISA review manual 2014 page number 273 and 274

QUESTION 463

Which of the following term related to network performance refers to the maximum rate that information can be transferred over a network?

- A. Bandwidth
- B. Throughput
- C. Latency
- D. Jitter

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support In computer networks, bandwidth is often used as a synonym for data transfer rate - it is the amount of data that can be carried from one point to another in a given time period (usually a second).

This kind of bandwidth is usually expressed in bits (of data) per second (bps). Occasionally, it's expressed as bytes per second (Bps). A modem that works at 57,600 bps has twice the bandwidth of a modem that works at 28,800 bps. In general, a link with a high bandwidth is one that may be able to carry enough information to sustain the succession of images in a video presentation.

It should be remembered that a real communications path usually consists of a succession of links, each with its own bandwidth. If one of these is much slower than the rest, it is said to be a bandwidth bottleneck.

For your exam you should know below information about Network performance:

Network performance refers to measurement of service quality of a telecommunications product as seen by the customer.

The following list gives examples of network performance measures for a circuit-switched network and one type of packet-switched network (ATM):

Circuit-switched networks: In circuit switched networks, network performance is synonymous with the grade of service. The number of rejected calls is a measure of how well the network is performing under heavy traffic loads. Other types of performance measures can include noise, echo and so on.

ATM: In an Asynchronous Transfer Mode (ATM) network, performance can be measured by line rate, quality of service (QoS), data throughput, connect time, stability, technology, modulation technique and modem enhancements.

There are many different ways to measure the performance of a network, as each network is different in nature and design. Performance can also be modeled instead of measured; one example of this is using state transition diagrams to model queuing performance in a circuit-switched network. These diagrams allow the network planner to analyze how the network will perform in each state, ensuring that the network will be optimally designed.

The following measures are often considered important:

Bandwidth - Bandwidth is commonly measured in bits/second is the maximum rate that information can be transferred
Throughput - Throughput is the actual rate that information is transferred
Latency - Latency is the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any node the information traverses
Jitter - Jitter is the variation in the time of arrival at the receiver of the information
Error Rate - Error rate is the number of corrupted bits expressed as a percentage or fraction of the total sent

The following answers are incorrect:

Throughput - Throughput is the actual rate that information is transferred

Latency - Latency is the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any

nodes the information traverses

Jitter - Jitter is the variation in the time of arrival at the receiver of the information CISA review manual 2014 page number 275

QUESTION 464

Which of the following term related to network performance refers to the actual rate that information is transferred over a network?

- A. Bandwidth
- B. Throughput
- C. Latency
- D. Jitter

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Throughput the actual rate that information is transferred. In data transmission, throughput is the amount of data moved successfully from one place to another in a given time period.

For your exam you should know below information about Network performance:

Network performance refers to measurement of service quality of a telecommunications product as seen by the customer.

The following list gives examples of network performance measures for a circuit-switched network and one type of packet-switched network (ATM):

Circuit-switched networks: In circuit switched networks, network performance is synonymous with the grade of service. The number of rejected calls is a measure of how well the network is performing under heavy traffic loads. Other types of performance measures can include noise, echo and so on.

ATM: In an Asynchronous Transfer Mode (ATM) network, performance can be measured by line rate, quality of service (QoS), data throughput, connect time, stability, technology, modulation technique and modem enhancements.

There are many different ways to measure the performance of a network, as each network is different in nature and design. Performance can also be modeled instead of measured; one example of this is using state transition diagrams to model queuing performance in a circuit-switched network. These diagrams allow the network planner to analyze how the network will perform in each state, ensuring that the network will be optimally designed.

The following measures are often considered important:

Bandwidth - Bandwidth is commonly measured in bits/second is the maximum rate that information can be transferred

Throughput - Throughput is the actual rate that information is transferred Latency - Latency is the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any nodes the information traverses Jitter - Jitter is the variation in the time of arrival at the receiver of the information Error Rate - Error rate is the number of corrupted bits expressed as a percentage or fraction of the total sent

The following answers are incorrect:

Bandwidth - Bandwidth is commonly measured in bits/second is the maximum rate that information can be transferred

Latency - Latency is the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any nodes the information traverses

Jitter - Jitter is the variation in the time of arrival at the receiver of the information CISA review manual 2014 page number 275

QUESTION 465

Which of the following term related to network performance refers to the delay that packet may experience on their way to reach the destination from the source?

- A. Bandwidth
- B. Throughput
- C. Latency
- D. Jitter

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Latency the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any nodes the information traverses.

In a network, latency, a synonym for delay, is an expression of how much time it takes for a packet of data to get from one designated point to another. In some usages (for example, AT&T), latency is measured by

sending a packet that is returned to the sender and the round-trip time is considered the latency.

The latency assumption seems to be that data should be transmitted instantly between one point and another (that is, with no delay at all). The contributors to network latency include:

Propagation: This is simply the time it takes for a packet to travel between one place and another at the speed of light.

Transmission: The medium itself (whether optical fiber, wireless, or some other) introduces some delay. The size of the packet introduces delay in a round trip since a larger packet will take longer to receive and return than a short one.

Router and other processing: Each gateway node takes time to examine and possibly change the header in a packet (for example, changing the hop count in the time-to-live field). Other computer and storage delays: Within networks at each end of the journey, a packet may be subject to storage and hard disk access delays at intermediate devices such as switches and bridges. (In backbone statistics, however, this kind of latency is probably not considered.)

For your exam you should know below information about Network performance:

Network performance refers to measurement of service quality of a telecommunications product as seen by the customer.

The following list gives examples of network performance measures for a circuit-switched network and one type of packet-switched network (ATM):

Circuit-switched networks: In circuit switched networks, network performance is synonymous with the grade of service. The number of rejected calls is a measure of how well the network is performing under heavy traffic loads. Other types of performance measures can include noise, echo and so on.

ATM: In an Asynchronous Transfer Mode (ATM) network, performance can be measured by line rate, quality of service (QoS), data throughput, connect time, stability, technology, modulation technique and modem enhancements.

There are many different ways to measure the performance of a network, as each network is different in nature and design. Performance can also be modeled instead of measured; one example of this is using state transition diagrams to model queuing performance in a circuit-switched network. These diagrams allow the network planner to analyze how the network will perform in each state, ensuring that the network will be optimally designed.

The following measures are often considered important:

Bandwidth - Bandwidth is commonly measured in bits/second is the maximum rate that information can be transferred

Throughput - Throughput is the actual rate that information is transferred **Latency** - Latency is the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any nodes the information traverses **Jitter** - Jitter is the variation in the time of arrival at the receiver of the information **Error Rate** - Error rate is the number of corrupted bits expressed as a percentage or fraction of the total sent

The following answers are incorrect:

Bandwidth - Bandwidth is commonly measured in bits/second is the maximum rate that information can be transferred

Throughput - Throughput is the actual rate that information is transferred **Jitter** - Jitter is the variation in the time of arrival at the receiver of the information CISA review manual 2014 page number 275

QUESTION 466

Which of the following term related to network performance refers to the variation in the time of arrival of packets on the receiver of the information?

- A. Bandwidth
- B. Throughput
- C. Latency
- D. Jitter

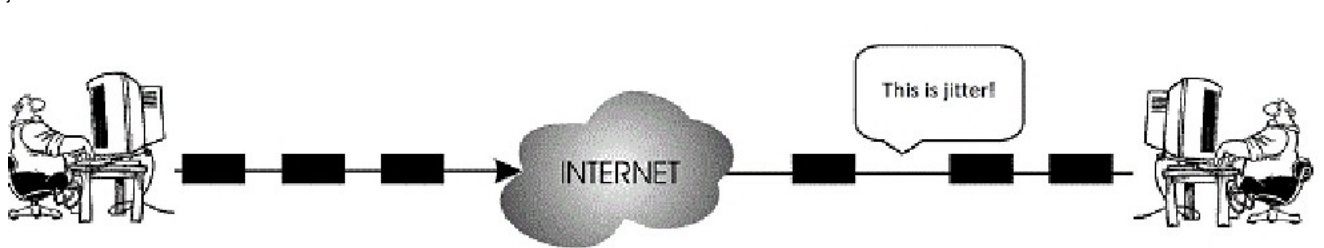
Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Simply said, the time difference in packet inter-arrival time to their destination can be called jitter. Jitter is specific issue that normally exists in packet switched networks and this phenomenon is usually not causing any communication problems. TCP/IP is responsible for dealing with the jitter impact on communication.

On the other hand, in VoIP network environment, or better say in any bigger environment today where we use IP phones on our network this can be a bigger problem. When someone is sending VoIP communication at a normal interval (let's say one frame every 10 ms) those packets can stuck somewhere in between inside the packet network and not arrive at expected regular peace to the destined station. That's the whole jitter phenomenon all about so we can say that the anomaly in tempo with which packet is expected and when it is in reality received is jitter.



In this image above, you can notice that the time it takes for packets to be send is not the same as the period in which the will arrive on the receiver side. One of the packets encounters some delay on his way and it is received little later than it was asumed. Here are the jitter buffers entering the story. They will mitigate packet delay if required. VoIP packets in networks have very changeable packet inter-arrival intervals because they are usually smaller than normal data packets and are therefore more numerous with bigger chance to get some delay along the way.

For your exam you should know below information about Network performance:

Network performance refers to measurement of service quality of a telecommunications product as seen by the customer.

The following list gives examples of network performance measures for a circuit-switched network and one type of packet-switched network (ATM):

Circuit-switched networks: In circuit switched networks, network performance is synonymous with the grade of service. The number of rejected calls is a measure of how well the network is performing under heavy traffic loads. Other types of performance measures can include noise, echo and so on.

ATM: In an Asynchronous Transfer Mode (ATM) network, performance can be measured by line rate, quality of service (QoS), data throughput, connect time, stability, technology, modulation technique and modem enhancements.

There are many different ways to measure the performance of a network, as each network is different in nature and design. Performance can also be modeled instead of measured; one example of this is using state transition diagrams to model queuing performance in a circuit-switched network. These diagrams allow the network planner to analyze how the network will perform in each state, ensuring that the network will be optimally designed.

The following measures are often considered important:

Bandwidth - Bandwidth is commonly measured in bits/second is the maximum rate that information can be transferred

Throughput - Throughput is the actual rate that information is transferred **Latency** - Latency is the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any nodes the information traverses **Jitter** - Jitter is the variation in the time of arrival at the receiver of the information **Error Rate** - Error rate is the number of corrupted bits expressed as a percentage or fraction of the total sent

The following answers are incorrect:

Bandwidth - Bandwidth is commonly measured in bits/second is the maximum rate that information can be transferred

Throughput - Throughput is the actual rate that information is transferred

Latency - Latency is the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any nodes the information traverses CISA review manual 2014 page number 275 and <http://howdoesinternetwork.com/2013/jitter>

QUESTION 467

Which of the following term related to network performance refers to the number of corrupted bits expressed as a percentage or fraction of the total sent?

- A. Bandwidth
- B. Throughput
- C. Latency
- D. Error Rate

Correct Answer: D
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Error rate is the number of corrupted bits expressed as a percentage or fraction of the total sent

For your exam you should know below information about Network performance:

Network performance refers to measurement of service quality of a telecommunications product as seen by the customer.

The following list gives examples of network performance measures for a circuit-switched network and one type of packet-switched network (ATM):

Circuit-switched networks: In circuit switched networks, network performance is synonymous with the grade of service. The number of rejected calls is a measure of how well the network is performing under heavy traffic loads. Other types of performance measures can include noise, echo and so on.

ATM: In an Asynchronous Transfer Mode (ATM) network, performance can be measured by line rate, quality of service (QoS), data throughput, connect time, stability, technology, modulation technique and modem enhancements.

There are many different ways to measure the performance of a network, as each network is different in nature and design. Performance can also be modeled instead of measured; one example of this is using state transition diagrams to model queuing performance in a circuit-switched network. These diagrams allow the network planner to analyze how the network will perform in each state, ensuring that the network will be optimally designed.

The following measures are often considered important:

Bandwidth - Bandwidth is commonly measured in bits/second is the maximum rate that information can be transferred

Throughput - Throughput is the actual rate that information is transferred Latency - Latency is the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any nodes the information traverses Jitter - Jitter is the variation in the time of arrival at the receiver of the information Error Rate - Error rate is the number of corrupted bits expressed as a percentage or fraction of the total sent

The following answers are incorrect:

Bandwidth - Bandwidth is commonly measured in bits/second is the maximum rate that information can be transferred

Throughput - Throughput is the actual rate that information is transferred

Latency - Latency is the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any nodes the information traverses CISA review manual 2014 page number 275

QUESTION 468

Which of the following term in business continuity determines the maximum acceptable amount of data loss measured in time?

- A. RPO
- B. RTO
- C. WRT
- D. MTD

Correct Answer: A
Explanation

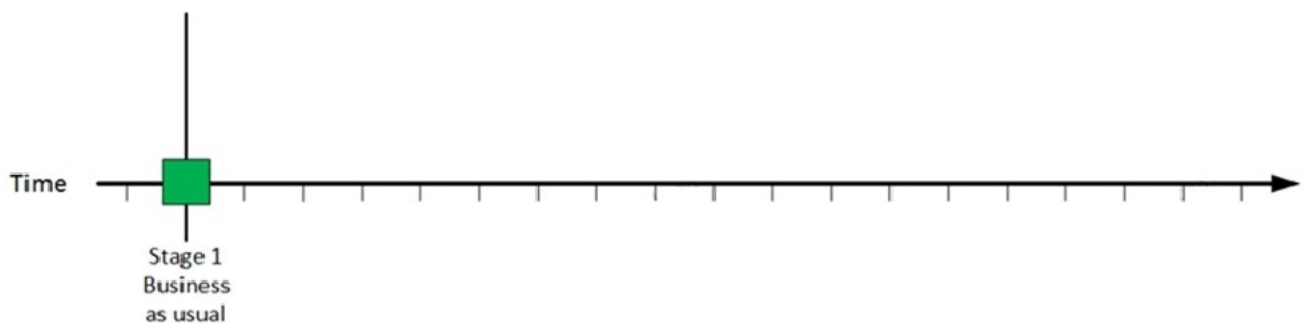
Explanation/Reference:

Section: Information System Operations, Maintenance and Support A recovery point objective, or "RPO", is defined by business continuity planning. It is the maximum tolerable period in which data might be lost from an IT service due to a major incident. The RPO gives systems designers a limit to work to. For instance, if the RPO is set to four hours, then in practice, off-site mirrored backups must be continuously maintained a daily off-site backup on tape will not suffice. Care must be taken

to avoid two common mistakes around the use and definition of RPO. Firstly, BC staff use business impact analysis to determine RPO for each service RPO is not determined by the existent backup regime. Secondly, when any level of preparation of off-site data is required, rather than at the time the backups are offsite, the period during which data is lost very often starts near the time of the beginning of the work to prepare backups which are eventually offsite.

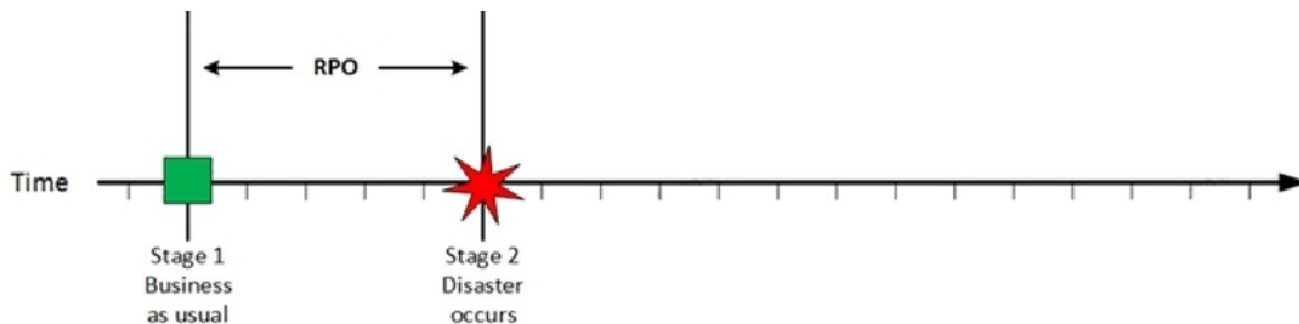
For your exam you should know below information about RPO, RTO, WRT and MTD:

Stage 1: Business as usual
 Business as usual



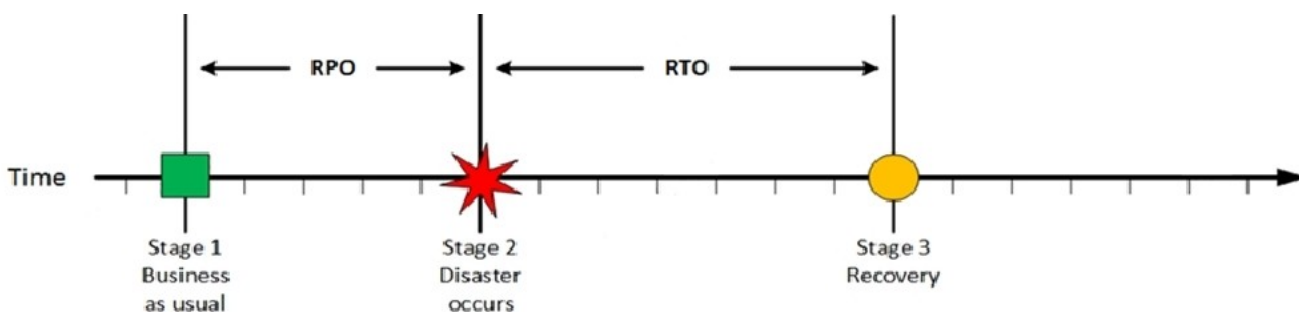
At this stage all systems are running production and working correctly.

Stage 2: Disaster occurs
 Disaster Occurs



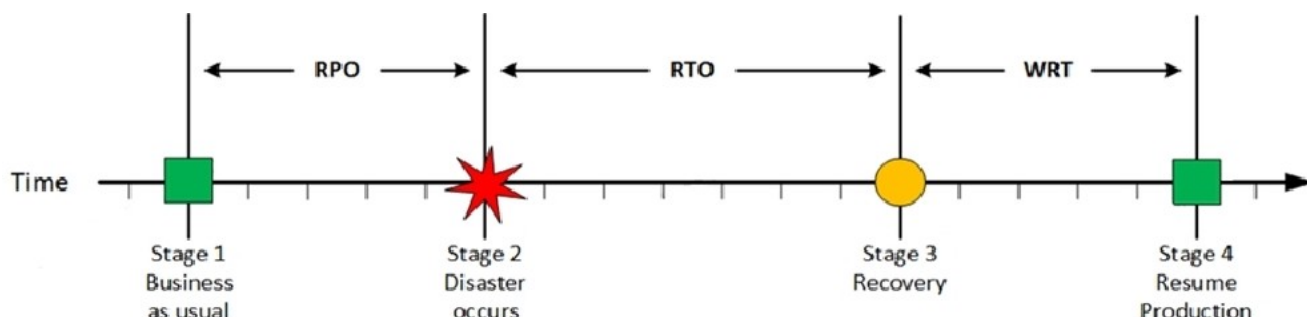
On a given point in time, disaster occurs and systems need to be recovered. At this point the Recovery Point Objective (RPO) determines the maximum acceptable amount of data loss measured in time. For example, the maximum tolerable data loss is 15 minutes.

Stage 3: Recovery
Recovery



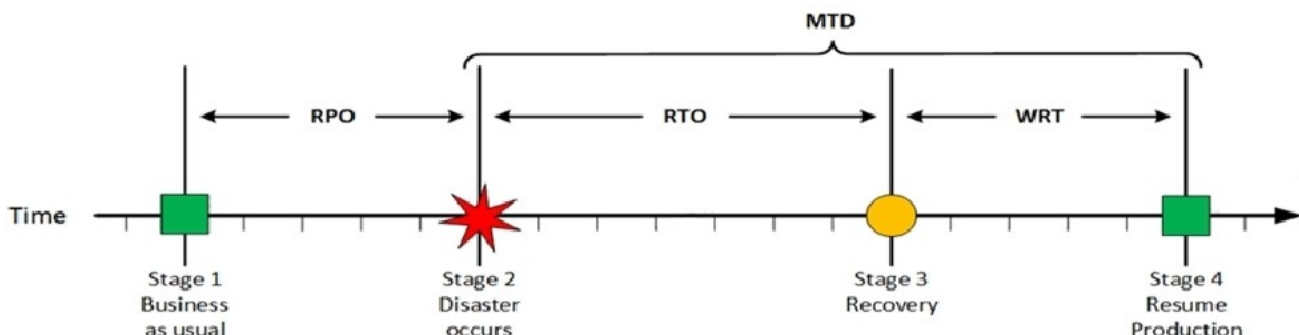
At this stage the system are recovered and back online but not ready for production yet. The Recovery Time Objective (RTO) determines the maximum tolerable amount of time needed to bring all critical systems back online. This covers, for example, restore data from back-up or fix of a failure. In most cases this part is carried out by system administrator, network administrator, storage administrator etc.

Stage 4: Resume Production
Resume Production



At this stage all systems are recovered, integrity of the system or data is verified and all critical systems can resume normal operations. The Work Recovery Time (WRT) determines the maximum tolerable amount of time that is needed to verify the system and/or data integrity. This could be, for example, checking the databases and logs, making sure the applications or services are running and are available. In most cases those tasks are performed by application administrator, database administrator etc. When all systems affected by the disaster are verified and/or recovered, the environment is ready to resume the production again.

MTD



The sum of RTO and WRT is defined as the Maximum Tolerable Downtime (MTD) which defines the total amount of time that a business process can be disrupted without causing any unacceptable consequences. This value should be defined by the business management team or someone like CTO, CIO or IT manager.

The following answers are incorrect:

RTO - The Recovery Time Objective (RTO) determines the maximum tolerable amount of time needed to bring all critical systems back online. This covers, for example, restore data from back-up or fix of a failure. In most cases this part is carried out by system administrator, network administrator, storage administrator etc.

WRT - The Work Recovery Time (WRT) determines the maximum tolerable amount of time that is needed to verify the system and/or data integrity. This could be, for example, checking the databases and logs, making sure the applications or services are running and are available. In most cases those tasks are performed by application administrator, database administrator etc. When all systems affected by the disaster are verified and/or recovered, the environment is ready to resume the production again.

MTD - The sum of RTO and WRT is defined as the Maximum Tolerable Downtime (MTD) which defines the

total amount of time that a business process can be disrupted without causing any unacceptable consequences. This value should be defined by the business management team or someone like CTO, CIO or IT manager.

CISA review manual 2014 page number 284

http://en.wikipedia.org/wiki/Recovery_point_objective

<http://defaultreasoning.com/2013/12/10/rpo-rto-wrt-mtdwth/>

QUESTION 469

Which of the following term in business continuity determines the maximum tolerable amount of time needed to bring all critical systems back online after disaster occurs?

- A. RPO
- B. RTO
- C. WRT
- D. MTD

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The recovery time objective (RTO) is the duration of time and a service level within which a business process must be restored after a disaster (or disruption) in order to avoid unacceptable consequences associated with a break in business continuity.

It can include the time for trying to fix the problem without a recovery, the recovery itself, testing, and the communication to the users. Decision time for users representative is not included.

The business continuity timeline usually runs parallel with an incident management timeline and may start at the same, or different, points.

In accepted business continuity planning methodology, the RTO is established during the Business Impact Analysis (BIA) by the owner of a process (usually in conjunction with the business continuity planner). The RTOs are then presented to senior management for acceptance.

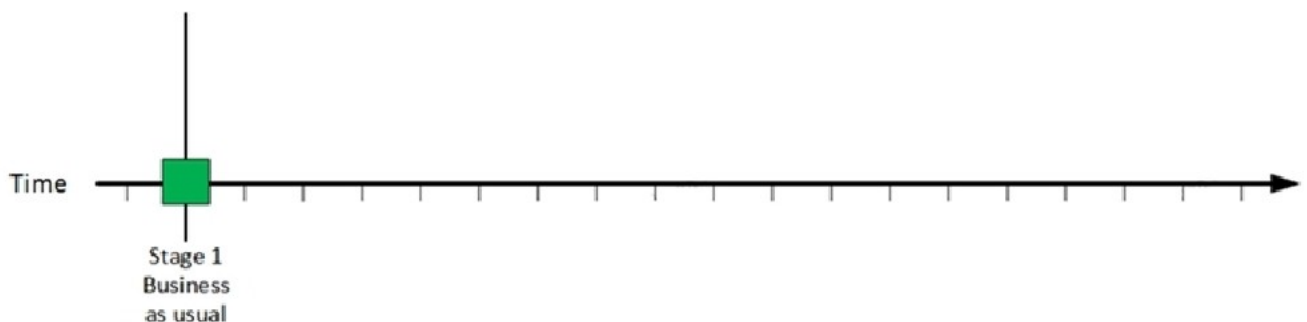
The RTO attaches to the business process and not the resources required to support the process.

The RTO and the results of the BIA in its entirety provide the basis for identifying and analyzing viable strategies for inclusion in the business continuity plan. Viable strategy options would include any which would enable resumption of a business process in a time frame at or near the RTO. This would include alternate or manual workaround procedures and would not necessarily require computer systems to meet the RTOs.

For your exam you should know below information about RPO, RTO, WRT and MTD :

Stage 1: Business as usual

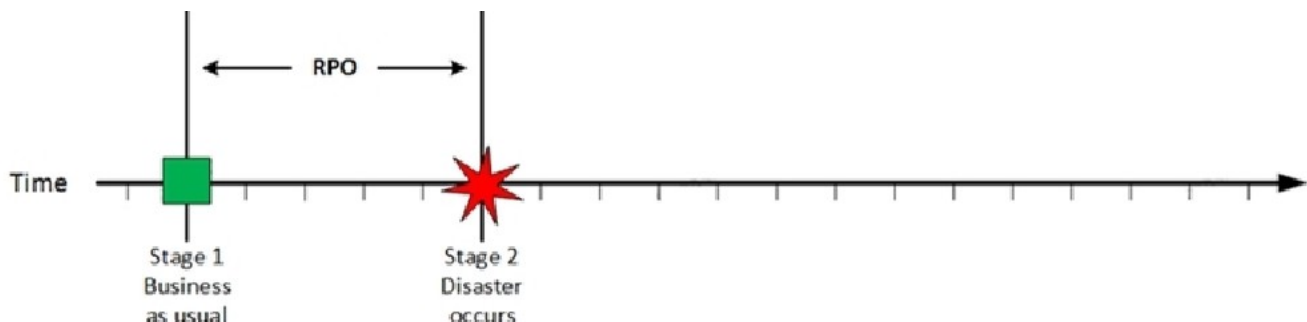
Business as usual



At this stage all systems are running production and working correctly.

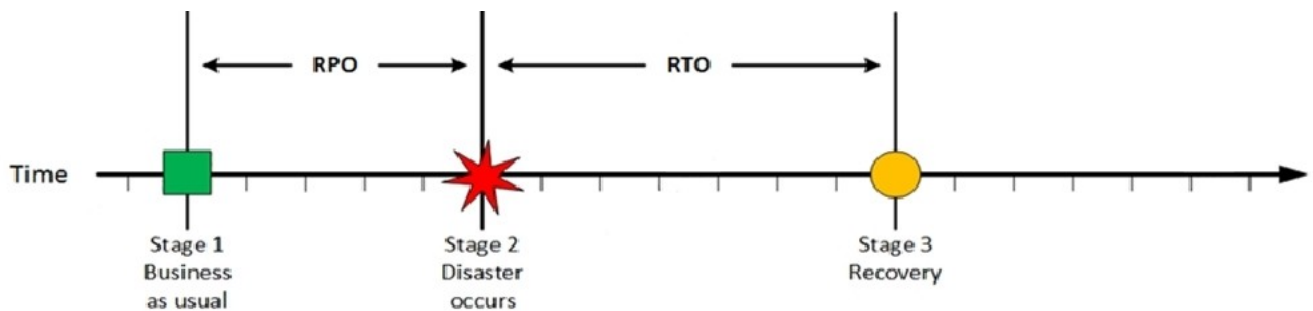
Stage 2: Disaster occurs

Disaster Occurs



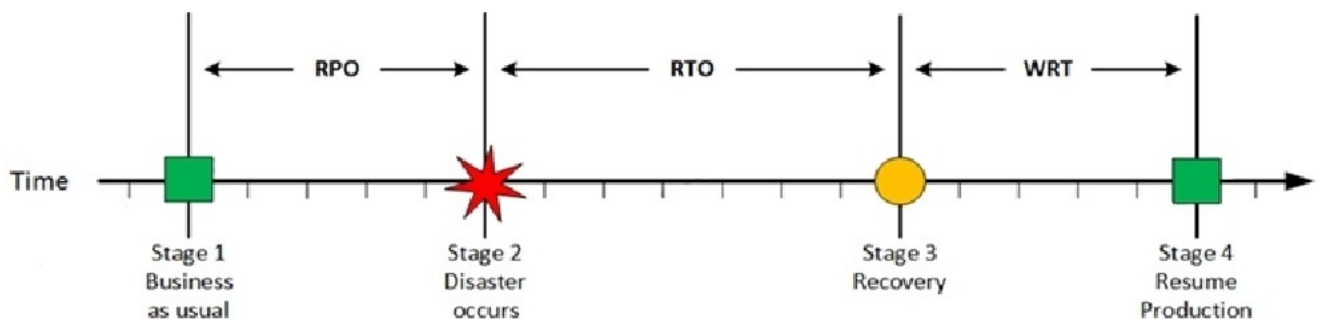
On a given point in time, disaster occurs and systems needs to be recovered. At this point the Recovery Point Objective (RPO) determines the maximum acceptable amount of data loss measured in time. For example, the maximum tolerable data loss is 15 minutes.

Stage 3: Recovery
Recovery



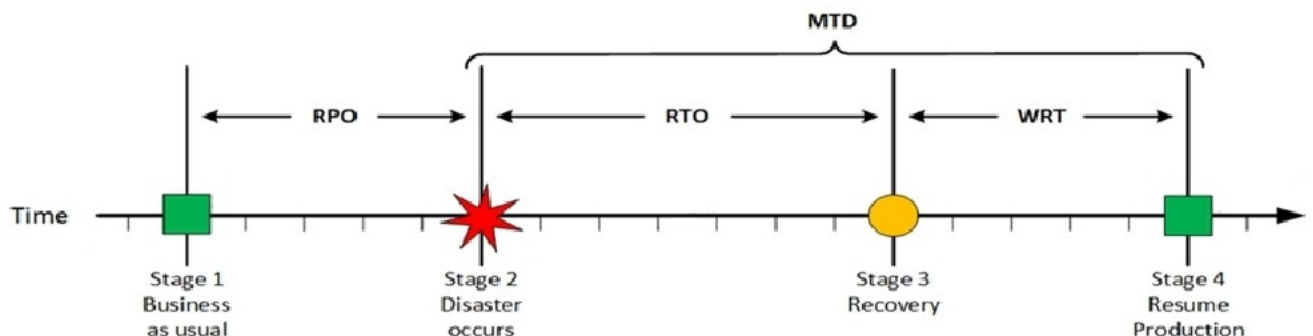
At this stage the system are recovered and back online but not ready for production yet. The Recovery Time Objective (RTO) determines the maximum tolerable amount of time needed to bring all critical systems back online. This covers, for example, restore data from back-up or fix of a failure. In most cases this part is carried out by system administrator, network administrator, storage administrator etc.

Stage 4: Resume Production
Resume Production



At this stage all systems are recovered, integrity of the system or data is verified and all critical systems can resume normal operations. The Work Recovery Time (WRT) determines the maximum tolerable amount of time that is needed to verify the system and/or data integrity. This could be, for example, checking the databases and logs, making sure the applications or services are running and are available. In most cases those tasks are performed by application administrator, database administrator etc. When all systems affected by the disaster are verified and/or recovered, the environment is ready to resume the production again.

MTD



The sum of RTO and WRT is defined as the Maximum Tolerable Downtime (MTD) which defines the total amount of time that a business process can be disrupted without causing any unacceptable consequences. This value should be defined by the business management team or someone like CTO, CIO or IT manager.

The following answers are incorrect:

RPO - Recovery Point Objective (RPO) determines the maximum acceptable amount of data loss measured in time. For example, the maximum tolerable data loss is 15 minutes.

WRT - The Work Recovery Time (WRT) determines the maximum tolerable amount of time that is needed to verify the system and/or data integrity. This could be, for example, checking the databases and logs, making sure the applications or services are running and are available. In most cases those tasks are performed by application administrator, database administrator etc. When all systems affected by the disaster are verified and/or recovered, the environment is ready to resume the production again.

MTD - The sum of RTO and WRT is defined as the Maximum Tolerable Downtime (MTD) which defines the total amount of time that a business process can be disrupted without causing any unacceptable consequences. This value should be defined by the business management team or someone like CTO, CIO or IT manager.

CISA review manual 2014 page number 284

http://en.wikipedia.org/wiki/Recovery_time_objective

<http://defaultreasoning.com/2013/12/10/rpo-rto-wrt-mtdwth/>

QUESTION 470

Which of the following term in business continuity determines the maximum tolerable amount of time that is needed to verify the system and/or data integrity?

- A. RPO
- B. RTO
- C. WRT
- D. MTD

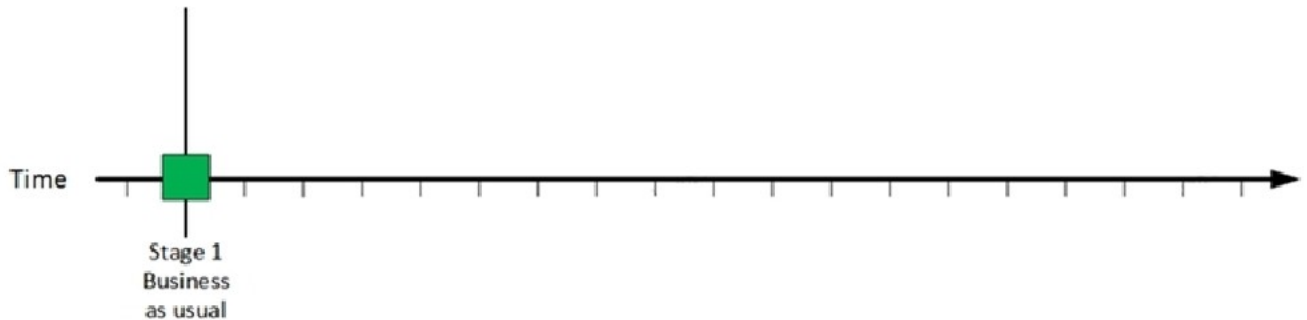
Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support The Work Recovery Time (WRT) determines the maximum tolerable amount of time that is needed to verify the system and/or data integrity. This could be, for example, checking the databases and logs, making sure the applications or services are running and are available. In most cases those tasks are performed by application administrator, database administrator etc. When all systems affected by the disaster are verified and/or recovered, the environment is ready to resume the production again.

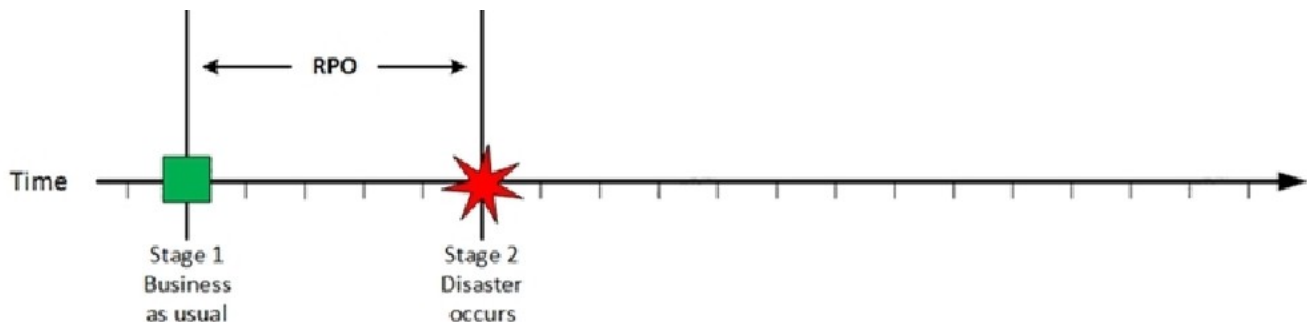
For your exam you should know below information about RPO, RTO, WRT and MTD:

Stage 1: Business as usual
Business as usual



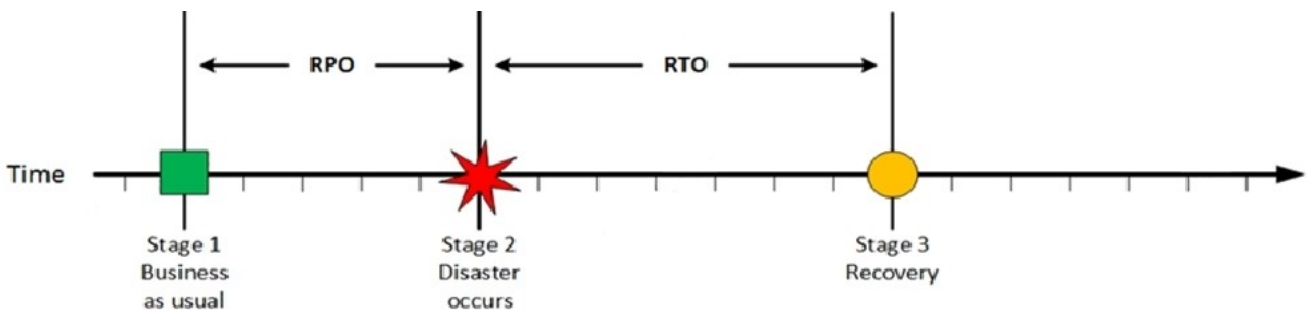
At this stage all systems are running production and working correctly.

Stage 2: Disaster occurs
Disaster Occurs



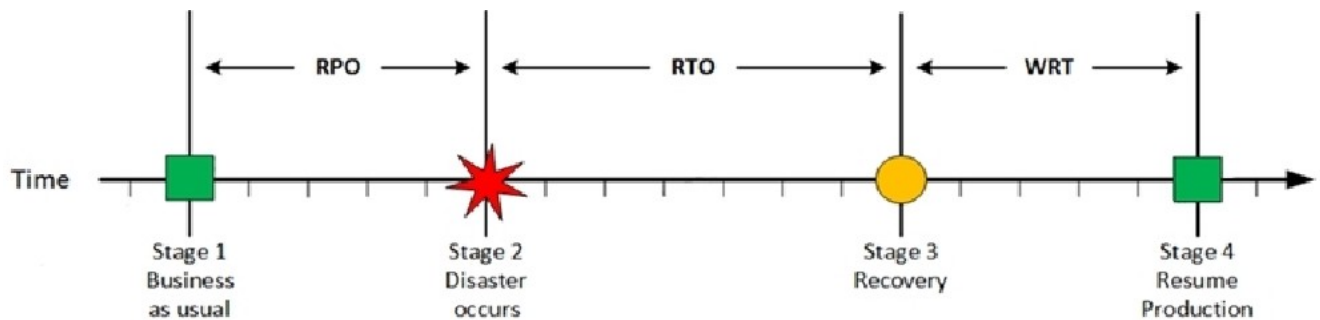
On a given point in time, disaster occurs and systems needs to be recovered. At this point the Recovery Point Objective (RPO) determines the maximum acceptable amount of data loss measured in time. For example, the maximum tolerable data loss is 15 minutes.

Stage 3: Recovery
Recovery



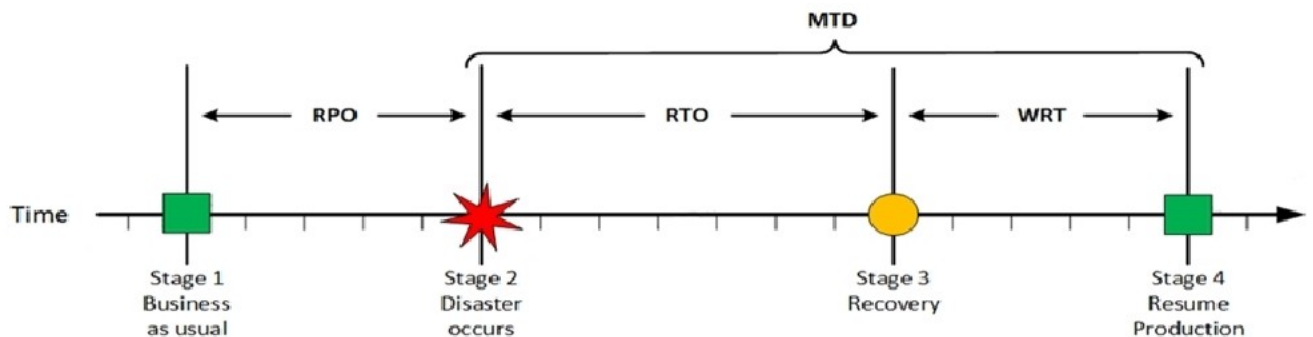
At this stage the system are recovered and back online but not ready for production yet. The Recovery Time Objective (RTO) determines the maximum tolerable amount of time needed to bring all critical systems back online. This covers, for example, restore data from back-up or fix of a failure. In most cases this part is carried out by system administrator, network administrator, storage administrator etc.

Stage 4: Resume Production
Resume Production



At this stage all systems are recovered, integrity of the system or data is verified and all critical systems can resume normal operations. The Work Recovery Time (WRT) determines the maximum tolerable amount of time that is needed to verify the system and/or data integrity. This could be, for example, checking the databases and logs, making sure the applications or services are running and are available. In most cases those tasks are performed by application administrator, database administrator etc. When all systems affected by the disaster are verified and/or recovered, the environment is ready to resume the production again.

MTD



The sum of RTO and WRT is defined as the Maximum Tolerable Downtime (MTD) which defines the total amount of time that a business process can be disrupted without causing any unacceptable consequences. This value should be defined by the business management team or someone like CTO, CIO or IT manager.

The following answers are incorrect:

RPO - Recovery Point Objective (RPO) determines the maximum acceptable amount of data loss measured in time. For example, the maximum tolerable data loss is 15 minutes.

RTO - The Recovery Time Objective (RTO) determines the maximum tolerable amount of time needed to bring all critical systems back online. This covers, for example, restore data from back-up or fix of a failure. In most cases this part is carried out by system administrator, network administrator, storage administrator etc.

MTD - The sum of RTO and WRT is defined as the Maximum Tolerable Downtime (MTD) which defines the total amount of time that a business process can be disrupted without causing any unacceptable consequences. This value should be defined by the business management team or someone like CTO, CIO or IT manager.

CISA review manual 2014 page number 284
<http://defaultreasoning.com/2013/12/10/rpo-rto-wrt-mtdwth/>

QUESTION 471

Which of the following term in business continuity defines the total amount of time that a business process can be disrupted without causing any unacceptable consequences?

- A. RPO
- B. RTO
- C. WRT
- D. MTD

Correct Answer: D

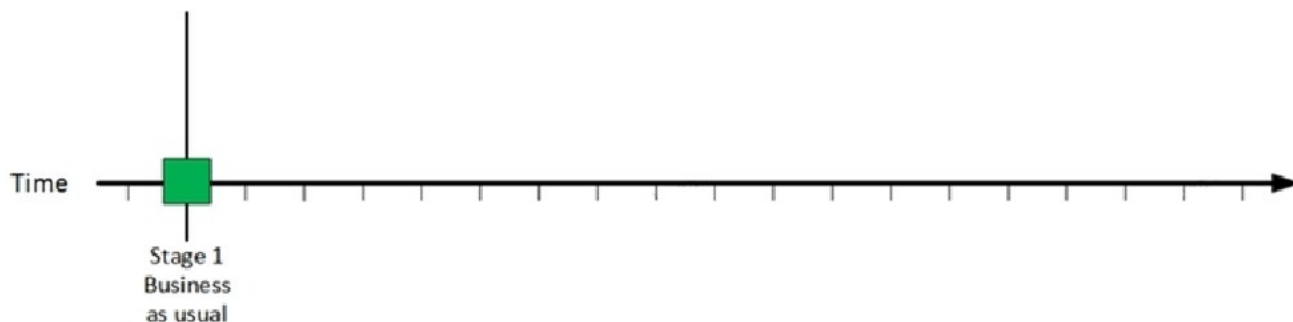
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The sum of RTO and WRT is defined as the Maximum Tolerable Downtime (MTD) which defines the total amount of time that a business process can be disrupted without causing any unacceptable consequences. This value should be defined by the business management team or someone like CTO, CIO or IT manager.

For your exam you should know below information about RPO, RTO, WRT and MTD:

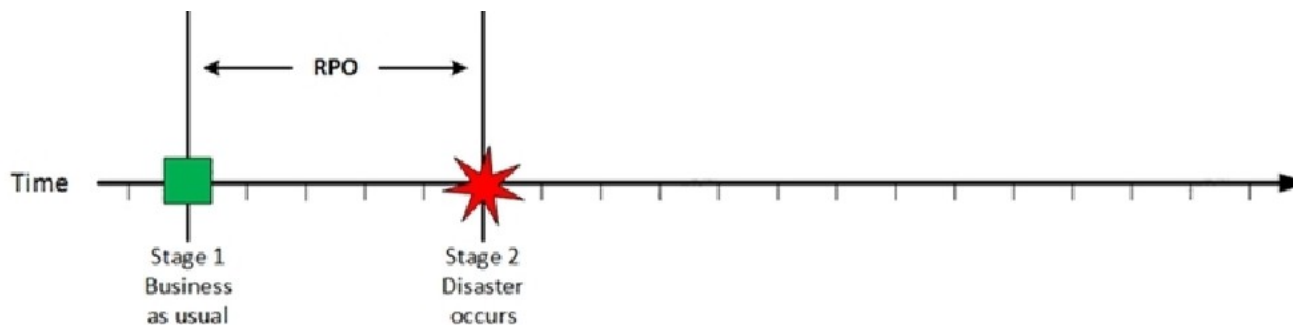
Stage 1: Business as usual
 Business as usual



At this stage all systems are running production and working correctly.

Stage 2: Disaster occurs

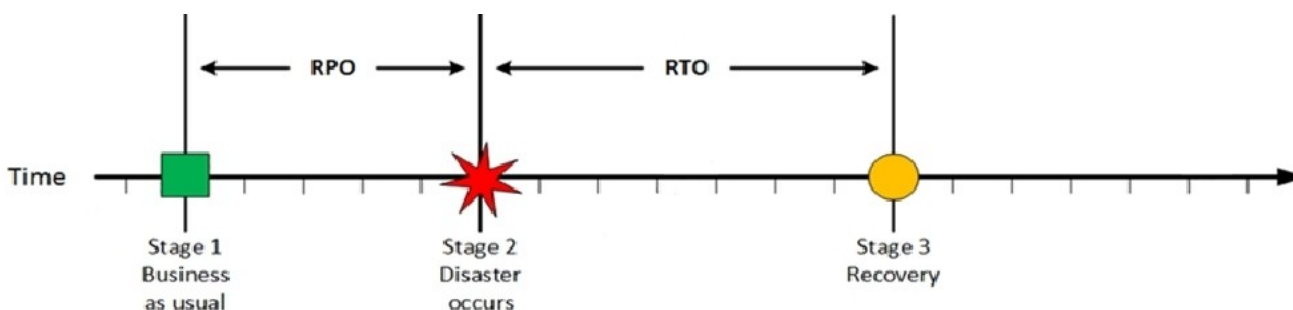
Disaster Occurs



On a given point in time, disaster occurs and systems need to be recovered. At this point the Recovery Point Objective (RPO) determines the maximum acceptable amount of data loss measured in time. For example, the maximum tolerable data loss is 15 minutes.

Stage 3: Recovery

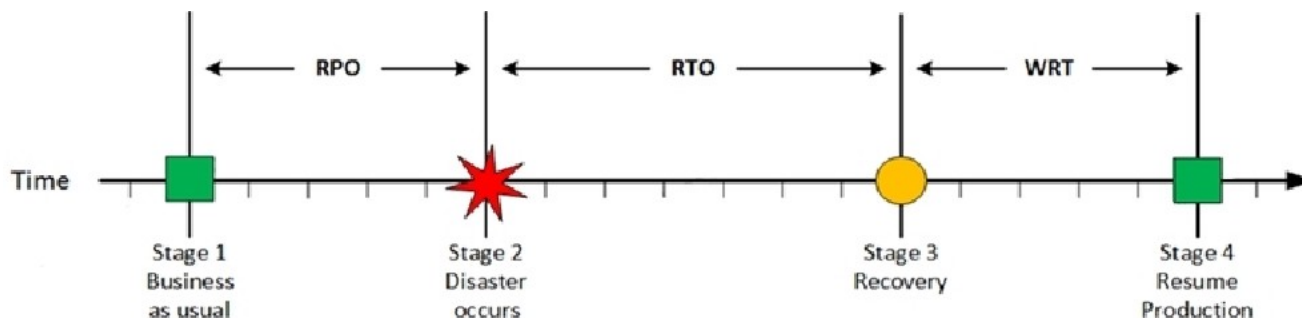
Recovery



At this stage the system are recovered and back online but not ready for production yet. The Recovery Time Objective (RTO) determines the maximum tolerable amount of time needed to bring all critical systems back online. This covers, for example, restore data from back-up or fix of a failure. In most cases this part is carried out by system administrator, network administrator, storage administrator etc.

Stage 4: Resume Production

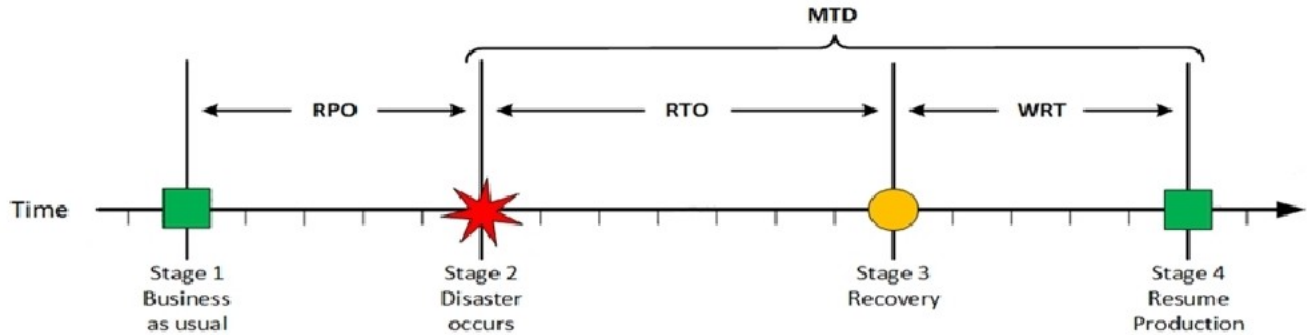
Resume Production



At this stage all systems are recovered, integrity of the system or data is verified and all critical systems can resume normal operations. The Work Recovery Time (WRT) determines the maximum tolerable amount of time that is needed to verify the system and/or data integrity. This could be, for example, checking the databases and logs, making sure the applications or services are running and are available. In most cases those tasks are performed by application administrator, database administrator etc. When all systems affected

by the disaster are verified and/or recovered, the environment is ready to resume the production again.

MTD



The sum of RTO and WRT is defined as the Maximum Tolerable Downtime (MTD) which defines the total amount of time that a business process can be disrupted without causing any unacceptable consequences. This value should be defined by the business management team or someone like CTO, CIO or IT manager.

The following answers are incorrect:

RPO - Recovery Point Objective (RPO) determines the maximum acceptable amount of data loss measured in time. For example, the maximum tolerable data loss is 15 minutes.

RTO - The Recovery Time Objective (RTO) determines the maximum tolerable amount of time needed to bring all critical systems back online. This covers, for example, restore data from back-up or fix of a failure. In most cases this part is carried out by system administrator, network administrator, storage administrator etc.

WRT - The Work Recovery Time (WRT) determines the maximum tolerable amount of time that is needed to verify the system and/or data integrity. This could be, for example, checking the databases and logs, making sure the applications or services are running and are available. In most cases those tasks are performed by application administrator, database administrator etc. When all systems affected by the disaster are verified and/or recovered, the environment is ready to resume the production again.

CISA review manual 2014 page number 284

<http://defaultreasoning.com/2013/12/10/rpo-rto-wrt-mtdwth/>

QUESTION 472

Which of the following term in business continuity defines the total amount of time that a business process can be disrupted without causing any unacceptable consequences?

- A. RPO
- B. RTO
- C. WRT
- D. MTD

Correct Answer: D

Explanation

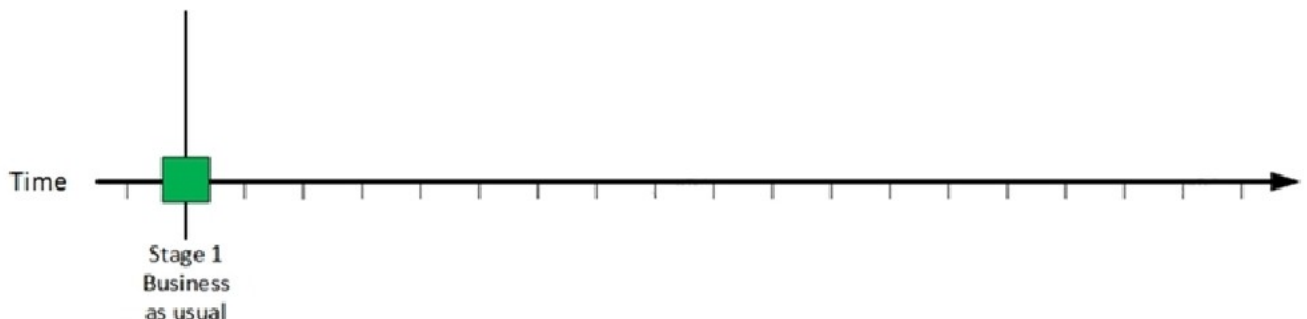
Explanation/Reference:

Section: Information System Operations, Maintenance and Support The sum of RTO and WRT is defined as the Maximum Tolerable Downtime (MTD) which defines the total

amount of time that a business process can be disrupted without causing any unacceptable consequences. This value should be defined by the business management team or someone like CTO, CIO or IT manager.

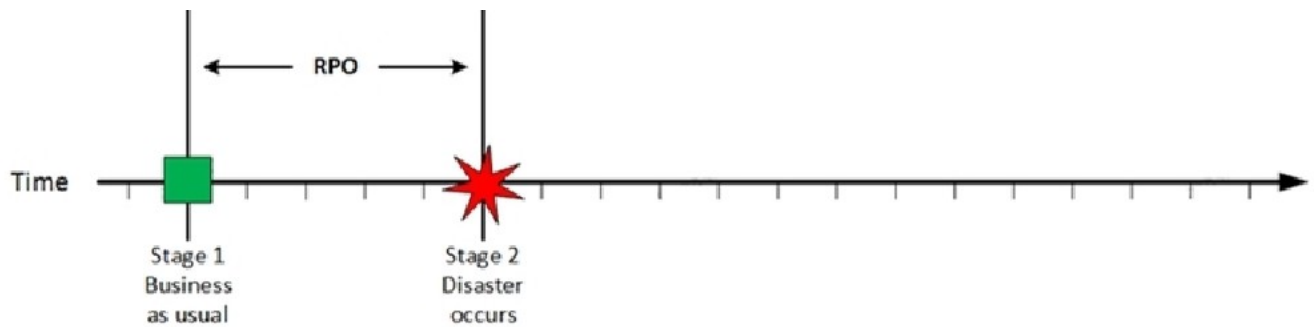
For your exam you should know below information about RPO, RTO, WRT and MTD:

Stage 1: Business as usual
Business as usual



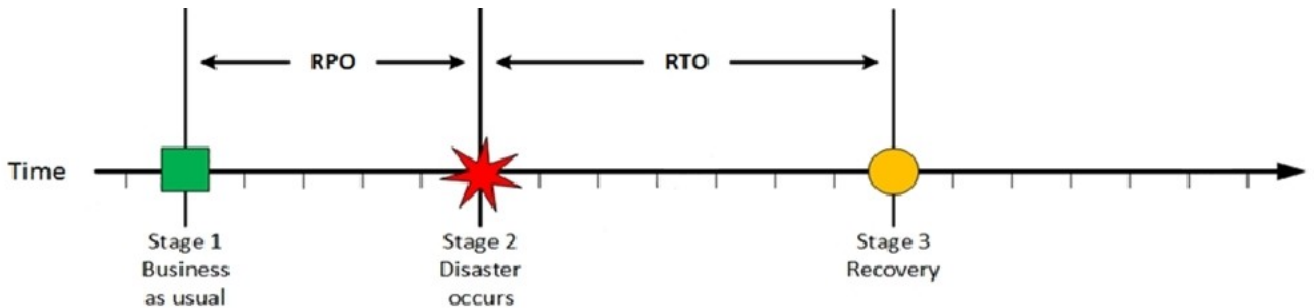
At this stage all systems are running production and working correctly.

Stage 2: Disaster occurs
Disaster Occurs



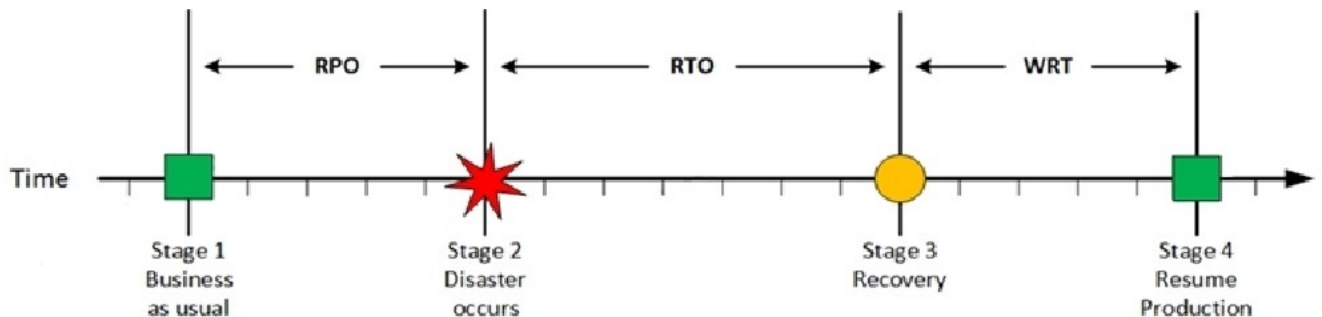
On a given point in time, disaster occurs and systems need to be recovered. At this point the Recovery Point Objective (RPO) determines the maximum acceptable amount of data loss measured in time. For example, the maximum tolerable data loss is 15 minutes.

Stage 3: Recovery
Recovery



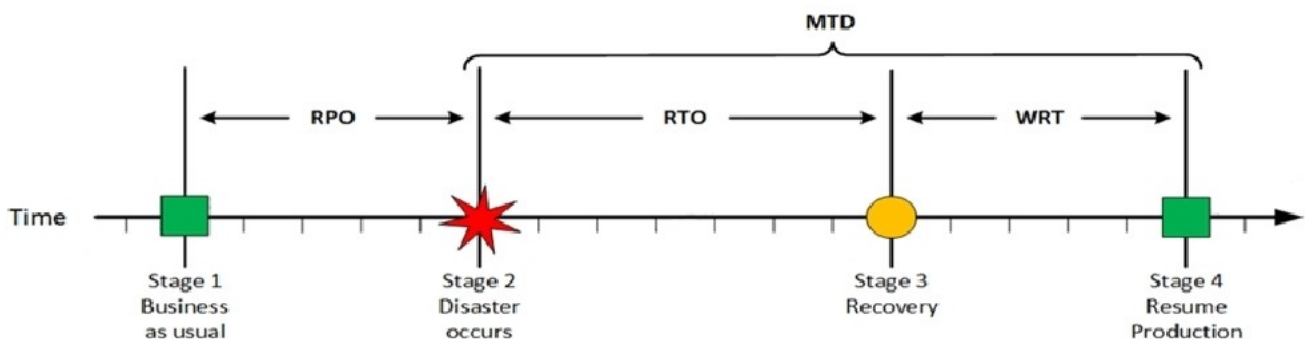
At this stage the system is recovered and back online but not ready for production yet. The Recovery Time Objective (RTO) determines the maximum tolerable amount of time needed to bring all critical systems back online. This covers, for example, restore data from back-up or fix of a failure. In most cases this part is carried out by system administrator, network administrator, storage administrator etc.

Stage 4: Resume Production
Resume Production



At this stage all systems are recovered, integrity of the system or data is verified and all critical systems can resume normal operations. The Work Recovery Time (WRT) determines the maximum tolerable amount of time that is needed to verify the system and/or data integrity. This could be, for example, checking the databases and logs, making sure the applications or services are running and are available. In most cases those tasks are performed by application administrator, database administrator etc. When all systems affected by the disaster are verified and/or recovered, the environment is ready to resume the production again.

MTD



The sum of RTO and WRT is defined as the Maximum Tolerable Downtime (MTD) which defines the total amount of time that a business process can be disrupted without causing any unacceptable consequences. This value should be defined by the business management team or someone like CTO, CIO or IT manager.

The following answers are incorrect:

RPO - Recovery Point Objective (RPO) determines the maximum acceptable amount of data loss measured in time. For example, the maximum tolerable data loss is 15 minutes.

RTO - The Recovery Time Objective (RTO) determines the maximum tolerable amount of time needed to bring all critical systems back online. This covers, for example, restore data from back-up or fix of a failure. In most cases this part is carried out by system administrator, network administrator, storage administrator etc.

WRT - The Work Recovery Time (WRT) determines the maximum tolerable amount of time that is needed to verify the system and/or data integrity. This could be, for example, checking the databases and logs, making sure the applications or services are running and are available. In most cases those tasks are performed by application administrator, database administrator etc. When all systems affected by the disaster are verified and/or recovered, the environment is ready to resume the production again.

CISA review manual 2014 page number 284

<http://defaultreasoning.com/2013/12/10/rpo-rto-wrt-mtdwth/>

QUESTION 473

As an IS auditor it is very important to understand the importance of job scheduling. Which of the following statement is NOT true about job scheduler or job scheduling software?

- A. Job information is set up only once, which increase the probability of an error.
- B. Records are maintained of all job success and failures.
- C. Reliance on operator is reduced.
- D. Job dependencies are defined so that if a job fails, subsequent jobs relying on its output will not be processed.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The NOT keyword is used in this question. You need to find out an option which is not true about job scheduling.

Below are some advantages of job scheduling or using job scheduling software.

Job information is set up only once, reduce the probability of an error.

Records are maintained of all job success and failures.

Reliance on operator is reduced.

Job dependencies are defined so that if a job fails, subsequent jobs relying on its output will not be processed.

For your exam you should know the information below:

A job scheduler is a computer application for controlling unattended background program execution (commonly called batch processing).

Synonyms are batch system, Distributed Resource Management System (DRMS), and Distributed Resource Manager (DRM). Today's job schedulers, often termed workload automation, typically provide a graphical user interface and a single point of control for definition and monitoring of background executions in a distributed network of computers. Increasingly, job schedulers are required to orchestrate the integration of real-time business activities with traditional background IT processing across different operating system platforms and business application environments.

Job scheduling should not be confused with process scheduling, which is the assignment of currently running processes to CPUs by the operating system.

Basic features expected of job scheduler software include:

interfaces which help to define workflows and/or job dependencies automatic submission of executions

interfaces to monitor the executions

priorities and/or queues to control the execution order of unrelated jobs

If software from a completely different area includes all or some of those features, this software is consider to have job scheduling capabilities.

Most operating systems (such as Unix and Windows) provide basic job scheduling capabilities, for example:

cron. Web hosting services provide job scheduling capabilities through a control panel or a webcron solution. Many programs such as DBMS, backup, ERPs, and BPM also include relevant job-scheduling capabilities. Operating system ("OS") or point program supplied job-scheduling will not usually provide the ability to

schedule beyond a single OS instance or outside the remit of the specific program. Organizations needing to automate unrelated IT workload may also leverage further advanced features from a job scheduler, such as:

real-time scheduling based on external, unpredictable events

automatic restart and recovery in event of failures

alerting and notification to operations personnel

generation of incident reports

audit trails for regulatory compliance purposes

The following answers are incorrect:

The other options are correctly defined about job scheduling

CISA review manual 2014 page number 242

http://en.wikipedia.org/wiki/Job_scheduler

QUESTION 474

Which of the following type of computer has highest processing speed?

- A. Supercomputers
- B. Midrange servers
- C. Personal computers
- D. Thin client computers

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Supercomputers are very large and expensive computers with the highest processing speed, designed to be used for specialized purpose or fields that require extensive processing power.

A supercomputer is focused on performing tasks involving intense numerical calculations such as weather forecasting, fluid dynamics, nuclear simulations, theoretical astrophysics, and complex scientific computations.

A supercomputer is a computer that is at the frontline of current processing capacity, particularly speed of calculation. The term supercomputer itself is rather fluid, and the speed of today's supercomputers tends to become typical of tomorrow's ordinary computer. Supercomputer processing speeds are measured in floating point operations per second, or FLOPS.

An example of a floating point operation is the calculation of mathematical equations in real numbers. In terms of computational capability, memory size and speed, I/O technology, and topological issues such as bandwidth and latency, supercomputers are the most powerful, are very expensive, and not cost-effective just to perform batch or transaction processing. Transaction processing is handled by less powerful computers such as server computers or mainframes.

For your exam you should know the information below:

Common Types of computers

Supercomputers

A supercomputer is focused on performing tasks involving intense numerical calculations such as weather forecasting, fluid dynamics, nuclear simulations, theoretical astrophysics, and complex scientific computations. A supercomputer is a computer that is at the frontline of current processing capacity, particularly speed of calculation. The term supercomputer itself is rather fluid, and the speed of today's supercomputers tends to

become typical of tomorrow's ordinary computer. Supercomputer processing speeds are measured in floating point operations per second, or FLOPS. An example of a floating point operation is the calculation of mathematical equations in real numbers. In terms of computational capability, memory size and speed, I/O technology, and topological issues such as bandwidth and latency, supercomputers are the most powerful, are very expensive, and not cost-effective just to perform batch or transaction processing. Transaction processing is handled by less powerful computers such as server computers or mainframes.

Mainframes

The term mainframe computer was created to distinguish the traditional, large, institutional computer intended to service multiple users from the smaller, single user machines. These computers are capable of handling and processing very large amounts of data quickly. Mainframe computers are used in large institutions such as government, banks and large corporations. They are measured in MIPS (million instructions per second) and respond to up to 100s of millions of users at a time.

Mid-range servers

Midrange systems are primarily high-end network servers and other types of servers that can handle the large-scale processing of many business applications. Although not as powerful as mainframe computers, they are less costly to buy, operate, and maintain than mainframe systems and thus meet the computing needs of many organizations. Midrange systems have become popular as powerful network servers to help manage large Internet Web sites, corporate intranets and extranets, and other networks. Today, midrange systems include servers used in industrial process-control and manufacturing plants and play major roles in computer-aided manufacturing (CAM). They can also take the form of powerful technical workstations for computer-aided design (CAD) and other computation and graphics-intensive applications. Midrange system are also used as front-end servers to assist mainframe computers in telecommunications processing and network management.

Personal computers

A personal computer (PC) is a general-purpose computer, whose size, capabilities and original sale price makes it useful for individuals, and which is intended to be operated directly by an end-user with no intervening computer operator. This contrasted with the batch processing or time-sharing models which allowed larger, more expensive minicomputer and mainframe systems to be used by many people, usually at the same time. Large data processing systems require a full-time staff to operate efficiently.

Laptop computers

A laptop is a portable personal computer with a clamshell form factor, suitable for mobile use.[1] They are also sometimes called notebook computers or notebooks. Laptops are commonly used in a variety of settings, including work, education, and personal multimedia.

A laptop combines the components and inputs as a desktop computer; including display, speakers, keyboard, and pointing device (such as a touchpad), into a single device. Most modern-day laptop computers also have a webcam and a mice (microphone) pre-installed. [citation needed] A laptop can be powered either from a rechargeable battery, or by mains electricity via an AC adapter. Laptops are a diverse category of devices, and other more specific terms, such as ultra-books or net books, refer to specialist types of laptop which have been optimized for certain uses. Hardware specifications change vastly between these classifications, forgoing greater and greater degrees of processing power to reduce heat emissions.

Smartphone, tablets and other handheld devices

A mobile device (also known as a handheld computer or simply handheld) is a small, handheld computing device, typically having a display screen with touch input and/or a miniature keyboard. A handheld computing device has an operating system (OS), and can run various types of application software, known as apps. Most handheld devices can also be equipped with Wi-Fi, Bluetooth, and GPS capabilities that can allow connections to the Internet and other Bluetooth-capable devices, such as an automobile or a microphone headset. A camera or media player feature for video or music files can also be typically found on these devices along with a stable battery power source such as a lithium battery.

Early pocket-sized devices were joined in the late 2000s by larger but otherwise similar tablet computers. Much like in a personal digital assistant (PDA), the input and output of modern mobile devices are often combined into a touch-screen interface.

Smartphone's and PDAs are popular amongst those who wish to use some of the powers of a conventional computer in environments where carrying one would not be practical. Enterprise digital assistants can further extend the available functionality for the business user by offering integrated data capture devices like barcode, RFID and smart card readers.

Thin Client computers

A thin client (sometimes also called a lean, zero or slim client) is a computer or a computer program that depends heavily on some other computer (its server) to fulfill its computational roles. This is different from the traditional fat client, which is a computer designed to take on these roles by itself. The specific roles assumed by the server may vary, from providing data persistence (for example, for diskless nodes) to actual information processing on the client's behalf.

The following answers are incorrect:

Mid-range servers- Midrange systems are primarily high-end network servers and other types of servers that can handle the large-scale processing of many business applications. Although not as powerful as mainframe computers, they are less costly to buy, operate, and maintain than mainframe systems and thus meet the computing needs of many organizations. Midrange systems have become popular as powerful network servers to help manage large Internet Web sites, corporate intranets and extranets, and other networks. Today, midrange systems include servers used in industrial process-control and manufacturing plants and play major roles in computer-aided manufacturing (CAM).

Personal computers - A personal computer (PC) is a general-purpose computer, whose size, capabilities and original sale price makes it useful for individuals, and which is intended to be operated directly by an end-user with no intervening computer operator. This contrasted with the batch processing or time-sharing models which allowed larger, more expensive minicomputer and mainframe systems to be used by many people, usually at the same time. Large data processing systems require a full-time staff to operate efficiently.

Thin Client computers- A thin client (sometimes also called a lean, zero or slim client) is a computer or a computer program that depends heavily on some other computer (its server) to fulfill its computational roles. This is different from the traditional fat client, which is a computer designed to take on these roles by itself. The specific roles assumed by the server may vary, from providing data persistence (for example, for diskless nodes) to actual information processing on the client's behalf.

CISA review manual 2014 page number 246

http://en.wikipedia.org/wiki/Thin_client

http://en.wikipedia.org/wiki/Mobile_device

http://en.wikipedia.org/wiki/Personal_computer

http://en.wikipedia.org/wiki/Classes_of_computers

<http://en.wikipedia.org/wiki/Laptop>

QUESTION 475

Which of the following type of computer is a large, general purpose computer that are made to share their processing power and facilities with thousands of internal or external users?

- A. Thin client computer
- B. Midrange servers
- C. Personal computers
- D. Mainframe computers

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Mainframe computer is a large, general purpose computer that are made to share their processing power and facilities with thousands of internal or external users. The term mainframe computer was created to distinguish the traditional, large, institutional computer intended to service multiple users from the smaller, single user machines. These computers are capable of handling and processing very large amounts of data quickly. Mainframe computers are used in large institutions such as government, banks and large corporations. They are measured in MIPS (million instructions per second) and respond to up to 100s of millions of users at a time.

For your exam you should know the information below:

Common Types of computers

Supercomputers

A supercomputer is focused on performing tasks involving intense numerical calculations such as weather forecasting, fluid dynamics, nuclear simulations, theoretical astrophysics, and complex scientific computations. A supercomputer is a computer that is at the frontline of current processing capacity, particularly speed of calculation. The term supercomputer itself is rather fluid, and the speed of today's supercomputers tends to become typical of tomorrow's ordinary computer. Supercomputer processing speeds are measured in floating point operations per second, or FLOPS. An example of a floating point operation is the calculation of mathematical equations in real numbers. In terms of computational capability, memory size and speed, I/O technology, and topological issues such as bandwidth and latency, supercomputers are the most powerful, are very expensive, and not cost-effective just to perform batch or transaction processing. Transaction processing is handled by less powerful computers such as server computers or mainframes.

Mainframes

The term mainframe computer was created to distinguish the traditional, large, institutional computer intended to service multiple users from the smaller, single user machines. These computers are capable of handling and processing very large amounts of data quickly. Mainframe computers are used in large institutions such as government, banks and large corporations. They are measured in MIPS (million instructions per second) and respond to up to 100s of millions of users at a time.

Mid-range servers

Midrange systems are primarily high-end network servers and other types of servers that can handle the large-scale processing of many business applications. Although not as powerful as mainframe computers, they are less costly to buy, operate, and maintain than mainframe systems and thus meet the computing needs of many organizations. Midrange systems have become popular as powerful network servers to help manage large Internet Web sites, corporate intranets and extranets, and other networks. Today, midrange systems include servers used in industrial process-control and manufacturing plants and play major roles in computer-aided manufacturing (CAM). They can also take the form of powerful technical workstations for computer-aided design (CAD) and other computation and graphics-intensive applications. Midrange system are also used as front-end servers to assist mainframe computers in telecommunications processing and network management.

Personal computers

A personal computer (PC) is a general-purpose computer, whose size, capabilities and original sale price makes it useful for individuals, and which is intended to be operated directly by an end-user with no intervening computer operator. This contrasted with the batch processing or time-sharing models which allowed larger, more expensive minicomputer and mainframe systems to be used by many people, usually at the same time. Large data processing systems require a full-time staff to operate efficiently.

Laptop computers

A laptop is a portable personal computer with a clamshell form factor, suitable for mobile use.[1] They are also sometimes called notebook computers or notebooks. Laptops are commonly used in a variety of settings, including work, education, and personal multimedia.

A laptop combines the components and inputs as a desktop computer; including display, speakers, keyboard, and pointing device (such as a touchpad), into a single device. Most modern-day laptop computers also have a webcam and a mice (microphone) pre-installed. [citation needed] A laptop can be powered either from a rechargeable battery, or by mains electricity via an AC adapter. Laptops are a diverse category of devices, and other more specific terms, such as ultra-books or net books, refer to specialist types of laptop which have been optimized for certain uses. Hardware specifications change vastly between these classifications, forgoing greater and greater degrees of processing power to reduce heat emissions.

Smartphone, tablets and other handheld devices

A mobile device (also known as a handheld computer or simply handheld) is a small, handheld computing device, typically having a display screen with touch input and/or a miniature keyboard. A handheld computing device has an operating system (OS), and can run various types of application software, known as apps. Most handheld devices can also be equipped with Wi-Fi, Bluetooth, and GPS capabilities that can allow connections to the Internet and other Bluetooth-capable devices, such as an automobile or a microphone headset. A camera or media player feature for video or music files can also be typically found on these devices along with a stable battery power source such as a lithium battery.

Early pocket-sized devices were joined in the late 2000s by larger but otherwise similar tablet computers. Much like in a personal digital assistant (PDA), the input and output of modern mobile devices are often combined into a touch-screen interface.

Smartphone's and PDAs are popular amongst those who wish to use some of the powers of a conventional computer in environments where carrying one would not be practical. Enterprise digital assistants can further extend the available functionality for the business user by offering integrated data capture devices like barcode, RFID and smart card readers.

Thin Client computers

A thin client (sometimes also called a lean, zero or slim client) is a computer or a computer program that depends heavily on some other computer (its server) to fulfill its computational roles. This is different from the traditional fat client, which is a computer designed to take on these roles by itself. The specific roles assumed by the server may vary, from providing data persistence (for example, for diskless nodes) to actual information processing on the client's behalf.

The following answers are incorrect:

Mid-range servers- Midrange systems are primarily high-end network servers and other types of servers that can handle the large-scale processing of many business applications. Although not as powerful as mainframe computers, they are less costly to buy, operate, and maintain than mainframe systems and thus meet the computing needs of many organizations. Midrange systems have become popular as powerful network servers to help manage large Internet Web sites, corporate intranets and extranets, and other networks. Today, midrange systems include servers used in industrial process-control and manufacturing plants and play major roles in computer-aided manufacturing (CAM).
Personal computers - A personal computer (PC) is a general-purpose computer, whose size, capabilities and original sale price makes it useful for individuals, and which is intended to be operated directly by an end-user with no intervening computer operator. This contrasted with the batch processing or time-sharing models which allowed larger, more expensive minicomputer and mainframe systems to be used by many people, usually at the same time. Large data processing systems require a full-time staff to operate efficiently. Thin Client computers- A thin client (sometimes also called a lean, zero or slim client) is a computer or a computer program that depends heavily on some other computer (its server) to fulfill its computational roles. This is different from the traditional fat client, which is a computer designed to take on these roles by itself. The specific roles assumed by the server may vary, from providing data persistence (for example, for diskless

nodes) to actual information processing on the client's behalf.

CISA review manual 2014 page number 246

http://en.wikipedia.org/wiki/Thin_client

http://en.wikipedia.org/wiki/Mobile_device

http://en.wikipedia.org/wiki/Personal_computer

http://en.wikipedia.org/wiki/Classes_of_computers

<http://en.wikipedia.org/wiki/Laptop>

QUESTION 476

Diskless workstation is an example of:

- A. Handheld devices
- B. Thin client computer
- C. Personal computer
- D. Midrange server

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support
Diskless workstations are example of Thin client computer.

A thin client (sometimes also called a lean, zero or slim client) is a computer or a computer program that depends heavily on some other computer (its server) to fulfill its computational roles. This is different from the traditional fat client, which is a computer designed to take on these roles by itself. The specific roles assumed by the server may vary, from providing data persistence (for example, for diskless nodes) to actual information processing on the client's behalf.

For your exam you should know the information below:

Common Types of computers

Supercomputers

A supercomputer is focused on performing tasks involving intense numerical calculations such as weather forecasting, fluid dynamics, nuclear simulations, theoretical astrophysics, and complex scientific computations. A supercomputer is a computer that is at the frontline of current processing capacity, particularly speed of calculation. The term supercomputer itself is rather fluid, and the speed of today's supercomputers tends to become typical of tomorrow's ordinary computer. Supercomputer processing speeds are measured in floating point operations per second, or FLOPS. An example of a floating point operation is the calculation of mathematical equations in real numbers. In terms of computational capability, memory size and speed, I/O technology, and topological issues such as bandwidth and latency, supercomputers are the most powerful, are very expensive, and not cost-effective just to perform batch or transaction processing. Transaction processing is handled by less powerful computers such as server computers or mainframes.

Mainframes

The term mainframe computer was created to distinguish the traditional, large, institutional computer intended to service multiple users from the smaller, single user machines. These computers are capable of handling and processing very large amounts of data quickly. Mainframe computers are used in large institutions such as government, banks and large corporations. They are measured in MIPS (million instructions per second) and respond to up to 100s of millions of users at a time.

Mid-range servers

Midrange systems are primarily high-end network servers and other types of servers that can handle the large-scale processing of many business applications. Although not as powerful as mainframe computers, they are less costly to buy, operate, and maintain than mainframe systems and thus meet the computing needs of many organizations. Midrange systems have become popular as powerful network servers to help manage large Internet Web sites, corporate intranets and extranets, and other networks. Today, midrange systems include servers used in industrial process-control and manufacturing plants and play major roles in computer-aided manufacturing (CAM). They can also take the form of powerful technical workstations for computer-aided design (CAD) and other computation and graphics-intensive applications. Midrange system are also used as front-end servers to assist mainframe computers in telecommunications processing and network

management.

Personal computers

A personal computer (PC) is a general-purpose computer, whose size, capabilities and original sale price makes it useful for individuals, and which is intended to be operated directly by an end-user with no intervening computer operator. This contrasted with the batch processing or time-sharing models which allowed larger, more expensive minicomputer and mainframe systems to be used by many people, usually at the same time. Large data processing systems require a full-time staff to operate efficiently.

Laptop computers

A laptop is a portable personal computer with a clamshell form factor, suitable for mobile use.[1] They are also sometimes called notebook computers or notebooks. Laptops are commonly used in a variety of settings, including work, education, and personal multimedia.

A laptop combines the components and inputs as a desktop computer; including display, speakers, keyboard, and pointing device (such as a touchpad), into a single device. Most modern-day laptop computers also have a webcam and a mice (microphone) pre-installed. [citation needed] A laptop can be powered either from a rechargeable battery, or by mains electricity via an AC adapter. Laptops are a diverse category of devices, and other more specific terms, such as ultra-books or net books, refer to specialist types of laptop which have been optimized for certain uses. Hardware specifications change vastly between these classifications, forgoing greater and greater degrees of processing power to reduce heat emissions.

Smartphone, tablets and other handheld devices

A mobile device (also known as a handheld computer or simply handheld) is a small, handheld computing device, typically having a display screen with touch input and/or a miniature keyboard. A handheld computing device has an operating system (OS), and can run various types of application software, known as apps. Most handheld devices can also be equipped with Wi-Fi, Bluetooth, and GPS capabilities that can allow connections to the Internet and other Bluetooth-capable devices, such as an automobile or a microphone headset. A camera or media player feature for video or music files can also be typically found on these devices along with a stable battery power source such as a lithium battery.

Early pocket-sized devices were joined in the late 2000s by larger but otherwise similar tablet computers. Much like in a personal digital assistant (PDA), the input and output of modern mobile devices are often combined into a touch-screen interface.

Smartphone's and PDAs are popular amongst those who wish to use some of the powers of a conventional computer in environments where carrying one would not be practical. Enterprise digital assistants can further extend the available functionality for the business user by offering integrated data capture devices like barcode, RFID and smart card readers.

Thin Client computers

A thin client (sometimes also called a lean, zero or slim client) is a computer or a computer program that depends heavily on some other computer (its server) to fulfill its computational roles. This is different from the traditional fat client, which is a computer designed to take on these roles by itself. The specific roles assumed by the server may vary, from providing data persistence (for example, for diskless nodes) to actual information processing on the client's behalf.

The following answers are incorrect:

The other types of computers are not example of diskless workstation.

CISA review manual 2014 page number 246

http://en.wikipedia.org/wiki/Thin_client
http://en.wikipedia.org/wiki/Mobile_device
http://en.wikipedia.org/wiki/Personal_computer
http://en.wikipedia.org/wiki/Classes_of_computers
<http://en.wikipedia.org/wiki/Laptop>

QUESTION 477

In RFID technology which of the following risk could represent a threat to non-RFID networked or collocated systems, assets, and people?

- A. Business Process Risk
- B. Business Intelligence Risk
- C. Privacy Risk
- D. Externality Risk

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support RFID technology potentially could represent a threat to non-RFID networked or collocated systems, assets, and people.

RFID systems typically are not isolated from other systems and assets in the enterprise. Every connection point between the RFID system and something outside the RFID system represents a potential vulnerability for the entity on the other side of the connection, whether that is an application process, a valued asset, or a person.

Externality risks are present for both the RF and enterprise subsystems of an RFID system. The main externality risk for the RF subsystem is hazards resulting from electromagnetic radiation, which could possibly range from adverse human health effects to ignition of combustible material, such as fuel or ordnance.

The main externality risk for the enterprise subsystem is successful computer network attacks on networked devices and applications. Computer network attacks can involve malware (e.g., worms and viruses) or attack tools that exploit software vulnerabilities and configuration weaknesses to gain access to systems, perform a denial of service, or cause other damage.

The impact of computer network attacks can range from performance degradation to complete compromise of a mission-critical application. Because the externality risk by definition involves risks outside of the RFID system, it is distinct from both the business process and business intelligence risks; externality risks can be realized without having any effect on RFID-supported business processes or without revealing any information to adversaries.

For your exam you should know the information below:

Radio-frequency identification (RFID) is the wireless non-contact use of radio-frequency electromagnetic fields to transfer data, for the purposes of automatically identifying and tracking tags attached to objects. The tags contain electronically stored information. Some tags are powered by and read at short ranges (a few meters) via magnetic fields (electromagnetic induction). Others use a local power source such as a battery, or else have no battery but collect energy from the interrogating EM field, and then act as a passive transponder to emit microwaves or UHF radio waves (i.e., electromagnetic radiation at high frequencies). Battery powered tags may operate at hundreds of meters. Unlike a barcode, the tag does not necessarily need to be within line of sight of the reader, and may be embedded in the tracked object.

RFID tags are used in many industries. An RFID tag attached to an automobile during production can be used to track its progress through the assembly line. Pharmaceuticals can be tracked through warehouses. Livestock and pets may have tags injected, allowing positive identification of the animal.

RFID RISKS

RFID technology enables an organization to significantly change its business processes to:

Increase its efficiency, which results in lower costs, Increase its effectiveness, which improves mission performance and makes the implementing organization more resilient and better able to assign accountability, and Respond to customer requirements to use RFID technology to support supply chains and other applications.

The RFID technology itself is complex, combining a number of different computing and communications technologies to achieve the desired objectives. Unfortunately, both change and complexity generate risk.

For RFID implementations to be successful, organizations need to effectively manage that risk, which requires an understanding of its sources and its potential characteristics. This section reviews the major high-level business risks associated with RFID systems so that organizations planning or operating these systems can better identify, characterize, and manage the risk in their environments.

The risks are as follows:

Business Process Risk -Direct attacks on RFID system components potentially could undermine the business processes the RFID system was designed to enable.

Business Intelligence Risk- An adversary or competitor potentially could gain unauthorized access to RFID- generated information and use it to harm the interests of the organization implementing the RFID system. **Privacy Risk** - Personal privacy rights or expectations may be compromised if an RFID system uses what is considered personally identifiable information for a purpose other than originally intended or understood. The personal possession of functioning tags also is a privacy risk because it could enable tracking of those holding tagged items.

Externality Risk -RFID technology potentially could represent a threat to non-RFID networked or collocated systems, assets, and people. An important characteristic of RFID that impacts all of these risks is that RF communication is invisible to operators and users.

The following answers are incorrect:

Business Process Risk -Direct attacks on RFID system components potentially could undermine the business processes the RFID system was designed to enable.

Business Intelligence Risk- An adversary or competitor potentially could gain unauthorized access to RFID- generated information and use it to harm the interests of the organization implementing the RFID system.

Privacy Risk - Personal privacy rights or expectations may be compromised if an RFID system uses what is considered personally identifiable information for a purpose other than originally intended or understood. The personal possession of functioning tags also is a privacy risk because it could enable tracking of those holding tagged items.

CISA review manual 2014 page number 248

QUESTION 478

In which of the following RFID risks competitor potentially could gain unauthorized access to RFID-generated information and use it to harm the interests of the organization implementing the RFID system?

- A. Business Process Risk
- B. Business Intelligence Risk
- C. Privacy Risk
- D. Externality Risk

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support An adversary or competitor potentially could gain unauthorized access to RFID-generated information and use it to harm the interests of the organization implementing the RFID system.

RFID is a powerful technology, in part, because it supports wireless remote access to information about assets and people that either previously did not exist or was difficult to create or dynamically maintain. While this wireless remote access is a significant benefit, it also creates a risk that unauthorized parties could also have similar access to that information if proper controls are not in place. This risk is distinct from the business process risk because it can be realized even when business processes are functioning as intended.

A competitor or adversary can gain information from the RFID system in a number of ways, including eavesdropping on RF links between readers and tags, performing independent queries on tags to obtain relevant data, and obtaining unauthorized access to a back-end database storing information about tagged items. Supply chain applications may be particularly vulnerable to this risk because a variety of external entities may have read access to the tags or related databases.

The risk of unauthorized access is realized when the entity engaging in the unauthorized behavior does something harmful with that information. In some cases, the information may trigger an immediate response. For example, someone might use a reader to determine whether a shipping container holds expensive electronic equipment, and then break into the container when it gets a positive reading. This scenario is an example of targeting. In other cases, data might also be aggregated over time to provide intelligence regarding an organization's operations, business strategy, or proprietary methods.

For instance, an organization could monitor the number of tags entering a facility to provide a reasonable indication of its business growth or operating practices. In this case, if someone determined that a warehouse recently received a number of very large orders, then that might trigger an action in financial markets or prompt a competitor to change its prices or production schedule.

For your exam you should know the information below:

Radio-frequency identification (RFID) is the wireless non-contact use of radio-frequency electromagnetic fields to transfer data, for the purposes of automatically identifying and tracking tags attached to objects. The tags contain electronically stored information. Some tags are powered by and read at short ranges (a few meters) via magnetic fields (electromagnetic induction). Others use a local power source such as a battery, or else have no battery but collect energy from the interrogating EM field, and then act as a passive transponder to emit microwaves or UHF radio waves (i.e., electromagnetic radiation at high frequencies). Battery powered tags may operate at hundreds of meters. Unlike a barcode, the tag does not necessarily need to be within line of sight of the reader, and may be embedded in the tracked object.

RFID tags are used in many industries. An RFID tag attached to an automobile during production can be used to track its progress through the assembly line. Pharmaceuticals can be tracked through warehouses. Livestock and pets may have tags injected, allowing positive identification of the animal.

RFID RISKS

RFID technology enables an organization to significantly change its business processes to:

Increase its efficiency, which results in lower costs, Increase its effectiveness, which improves mission performance and makes the implementing organization more resilient and better able to assign accountability, and Respond to customer requirements to use RFID technology to support supply chains and other applications.

The RFID technology itself is complex, combining a number of different computing and communications technologies to achieve the desired objectives. Unfortunately, both change and complexity generate risk.

For RFID implementations to be successful, organizations need to effectively manage that risk, which requires an understanding of its sources and its potential characteristics. This section reviews the major high-level business risks associated with RFID systems so that organizations planning or operating these systems can better identify, characterize, and manage the risk in their environments.

The risks are as follows:

Business Process Risk -Direct attacks on RFID system components potentially could undermine the business processes the RFID system was designed to enable.

Business Intelligence Risk- An adversary or competitor potentially could gain unauthorized access to RFID- generated information and use it to harm the interests of the organization implementing the RFID system.

Privacy Risk - Personal privacy rights or expectations may be compromised if an RFID system uses what is considered personally identifiable information for a purpose other than originally intended or understood. The personal possession of functioning tags also is a privacy risk because it could enable tracking of those holding tagged items.

Externality Risk -RFID technology potentially could represent a threat to non-RFID networked or collocated systems, assets, and people. An important characteristic of RFID that impacts all of these risks is that RF communication is invisible to operators and users.

The following answers are incorrect:

Business Process Risk -Direct attacks on RFID system components potentially could undermine the business processes the RFID system was designed to enable.

Externality Risk -RFID technology potentially could represent a threat to non-RFID networked or collocated systems, assets, and people.

Privacy Risk - Personal privacy rights or expectations may be compromised if an RFID system uses what is considered personally identifiable information for a purpose other than originally intended or understood. The personal possession of functioning tags also is a privacy risk because it could enable tracking of those holding tagged items.

CISA review manual 2014 page number 248

QUESTION 479

John has been hired to fill a new position in one of the well-known financial institute. The position is for IS auditor. He has been assigned to complete IS audit of one of critical financial system. Which of the following should be the first step for John to be perform during IS audit planning?

- A. Perform risk assessment
- B. Determine the objective of the audit
- C. Gain an understanding of the business process
- D. Assign the personnel resource to audit

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support Determine the objective of audit should be the first step in the audit planning process. Depending upon the objective of an audit, auditor can gather the information about business process.

For CISA exam you should know the information below:

Steps to perform audit planning

Gain an understanding of the business mission, objectives, purpose and processes which includes information and processing requirement such as availability, integrity, security and business technology and information confidentiality.

Understand changes in the business environment audited.

Review prior work papers

Identify stated contents such as policies, standards and required guidelines, procedure and organization structures.

Perform a risk analysis to help in designing the audit plan.

Set the audit scope and audit objectives.

Develop the audit approach or audit strategy

Assign personnel resources to audit

Address engagement logistics.

The following answers are incorrect:

The other options specified should be completed once we finalize on the objective of audit. CISA review manual 2014 page number 30 (The process of auditing information system)

QUESTION 480

An IS auditor finds that a company is using a payroll provider hosted in a foreign country. Of the following, the MOST important audit consideration is whether the provider's operations:

- A. meet industry best practice and standards
- B. comply with applicable laws and regulations
- C. are shared with other companies using the provider
- D. are aligned with the company's culture

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 481

A business unit cannot achieve desired segregation of duties between operations and programming due to size constraints. Which of the following is MOST important for the IS auditor to identify?

- A. Unauthorized user controls
- B. Compensating controls
- C. Controls over operational effectiveness
- D. Additional control weaknesses

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 482

An organization has shifted from a bottom-up approach to a top-down approach in the development of IT policies. This should result in:

- A. a synthesis of existing operational policies
- B. greater consistency across the organization
- C. greater adherence to best practices
- D. a more comprehensive risk assessment plan

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 483

Which of the following weaknesses would have the GREATEST impact on the effective operation of a perimeter firewall?

- A. Ad-hoc monitoring of firewall activity
- B. Potential back doors to the firewall software
- C. Misconfiguration on the firewall rules
- D. Use of stateful firewalls with default configuration

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 484

An IS auditor is reviewing database log settings and notices that only INSERT and DELETE operations are being monitored in the database. What is the MOST significant risk?

- A. Metadata may not be logged

- B. Newly added records may not be logged
- C. Purged records may not be logged
- D. Changes to existing records may not be logged

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 485

Adding security requirements late in the software development life cycle would MOST likely result in:

- A. cost savings
- B. clearer understanding of requirements
- C. operational efficiency
- D. compensating controls

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 486

A reduction in which of the following would indicate improved performance in the administration of information security?

- A. IT security awareness training days
- B. Number of staff involved in security administration
- C. Systems subject to an intrusion detection process
- D. Turnaround time for requests for new user access

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 487

What is the PRIMARY objective of performing a vulnerability assessment following a business system update?

- A. Update the threat landscape
- B. Review the effectiveness of controls
- C. Determine operational losses
- D. Improve the change control process

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 488

Which of the following is an effective way to ensure the integrity of file transfers in a peer-to-peer (P2P) computing environment?

- A. Connect the client computers in the environment to a jump server.
- B. Ensure the files transferred through an intrusion detection system (IDS).
- C. Encrypt the packets shared between peers within the environment.
- D. Associate a message authentication code with each file transferred.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 489

Which of the following activities provides an IS auditor with the MOST insight regarding potential single person dependencies that might exist within the organization?

- A. Reviewing user activity logs
- B. Mapping IT processes to roles
- C. Reviewing vacation patterns
- D. Interviewing senior IT management

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 490

Which of the following ensures components of an IT system are identified and baselined, and that changes to them are implemented in a controlled manner?

- A. Restricted production access
- B. Configuration management process
- C. Change management process

D. Software versioning control

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 491
Which of the following is the BEST indication that an organization's vulnerability identification capability has achieved a high level of maturity?

- A. The organization collaborates with relevant partners to correlate vulnerability data.
- B. Known application vulnerabilities are manually categorized and prioritized.
- C. Vulnerability management tools are tailored for specific operating systems.
- D. Tools are in place to periodically identify new and updated vulnerabilities.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 492
Which of the following mechanisms for process improvement involves examination of industry best practice?

- A. Continuous improvement
- B. Knowledge management
- C. Business process reengineering (BPR)
- D. Benchmarking

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 493
An audit report notes that terminated employees have been retaining their access rights after their departure. Which of the following strategies would BEST ensure that obsolete access rights are identified in a timely manner?

- A. Delete user IDs at a predetermined date after their creation.
- B. Automatically delete user IDs after they are unused for a predetermined time.
- C. Implement an automated interface with the organization's human resources system.
- D. Require local supervisors to initiate connection.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 494
A small organization does not have enough employees to implement adequate segregation of duties in accounts payable. Which of the following is the BEST compensating control to mitigate the risk associated with this situation?

- A. Regular reconciliation of key transactions approved by a supervisor
- B. Supervisory review of logs to detect changes in vendors
- C. Review of transactions exceeding a specific threshold
- D. Rotation of duties among existing personnel

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 495
An IS auditor is following upon a finding that determined elevated administrator accounts for servers were not being properly checked out and then back in after each use. Which of the following is the MOST appropriate sampling technique to determine the scope of the problem?

- A. Stratified sampling
- B. Random sampling
- C. Attribute sampling
- D. Statistical sampling

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 496
Which of the following provides the BEST evidence that network filters are functioning?

- A. Reviewing network configuration rules
- B. Reviewing network filtering policy
- C. Performing network port scans

D. Analyzing network performance

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 497

An IS auditor performing an audit of backup procedures observes that backup tapes are picked up weekly and stored offsite at a third-party hosting facility. Which of the following recommendations would be the BEST way to maintain data integrity during transport?

- A. Ensure the data is transported in locked tamper-evident containers.
- B. Ensure that logging and recording of data transport takes place.
- C. Ensure the transport company is licensed and insured.
- D. Ensure the data is validated prior to transport.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 498

IT help desk statistics show a high number of recurring incidents with known solutions. Which of the following is the BEST IS audit recommendation?

- A. Outsource the IT help desk.
- B. Provide better training to end users.
- C. Implement incident escalation.
- D. Hire additional technical support staff.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 499

An organization outsourced its IS functions. To meet its responsibility for disaster recovery, the organization should:

- A. delegate evaluation of disaster recovery to internal audit.
- B. delegate evaluation of disaster recovery to a third party.
- C. discontinue the maintenance of the disaster recovery plan (DRP).
- D. coordinate disaster recovery administration with the outsourcing vendor.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 500

Which of the following is the BEST point in time to conduct a post-implementation review (PIR)?

- A. After a full processing cycle
- B. Immediately after deployment
- C. To coincide with annual PIR cycle
- D. Six weeks after deployment

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 501

Which of the following is the GREATEST cause for concern when an organization is planning to migrate business-critical applications to the cloud using a Platform as a Service (PaaS) model?

- A. The organization will not manage operating system patches.
- B. The cloud provider does not offer regional redundancy.
- C. Compliance requirements are not being validated.
- D. Application data will not be encrypted at rest.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 502

Due to limited storage capacity, an organization has decided to reduce the actual retention period for media containing completed low-value transactions. Which of the following is MOST important for the organization to ensure?

- A. The policy includes a strong risk-based approach.
- B. The retention period allows for review during the year-end audit.
- C. The total transaction amount has no impact on financial reporting.

D. The retention period complies with data owner responsibilities.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 503

During a review of operations, it is noted that during a batch update, an error was detected and the database initiated a roll-back. An IT operator stopped the roll-back and re-initiated the update. What should the operator have done PRIOR to re-initiating the update?

- A. Determined the cause of the error
- B. Obtained approval before re-initiating the update
- C. Allowed the roll-back to complete
- D. Scheduled the roll-back for a later time

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 504

Which of the following would provide the MOST important input during the planning phase for an audit on the implementation of a bring your own device (BYOD) program?

- A. Policies including BYOD acceptable use statements
- B. Results of a risk assessment
- C. An inventory of personal devices to be connected to the corporate network
- D. Findings from prior audits

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 505

Which of the following would present the GREATEST risk to the effectiveness of a security operations center for a global financial institution processing transactions 24x7?

- A. Incident response reporting is based on open source software.
- B. Incident response is conducted from a single location during normal business hours.
- C. Correlation of events excludes logs for pre-production systems.
- D. The incident response function is outsourced to a third-party provider.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 506

Which of the following functions is MOST likely to be performed by an operating system utility residing on a web server?

- A. Generating control totals for terminal devices such as point-of-sale devices.
- B. Configuring network protocols.
- C. Sending and receiving terminal warnings and error messages.
- D. Monitoring utilization activity and traffic patterns.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 507

Which of the following will provide the GREATEST assurance to IT management that a quality management system (QMS) is effective?

- A. A high percentage of incidents being quickly resolved
- B. A high percentage of stakeholders satisfied with the quality of IT
- C. A high percentage of IT processes reviewed by quality assurance
- D. A high percentage of IT employees attending quality training

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 508

A transaction processing system interfaces with the general ledger. Data analytics has identified that some transactions are being recorded twice in the general ledger. While management states a system fix has been implemented, what should the IS auditor recommend to validate the interface is working in the future?

- A. Perform periodic reconciliations.
- B. Ensure system owner sign-off for the system fix.
- C. Conduct functional testing.

D. Improve user acceptance testing (UAT).

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 509

Which of the following is the GREATEST risk of using a reciprocal site for disaster recovery?

- A. Inability to utilize the site when required
- B. Inability to test the recovery plans onsite
- C. Mismatched organizational security policies
- D. Equipment compatibility issues at the site

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 510

A financial institution suspects that a manager has been crediting customer accounts without authorization. Which of the following is the MOST effective method to validate this concern?

- A. Variable sampling
- B. Stop or go sampling
- C. Attribute sampling
- D. Discovery sampling

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 511

Which of the following is MOST likely to improve the portability of an application connected to a database?

- A. Analyzing stored procedures and triggers
- B. Optimizing the database physical schema
- C. Verifying database import and export procedures
- D. Using a structured query language (SQL)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 512

An organization is planning to outsource its customer relationship management (CRM) system to a Software as a Service (SaaS) provider. Which of the following is MOST important to include in the contract?

- A. Service levels for change management
- B. CRM system intellectual property rights
- C. Nondisclosure agreement
- D. Maximum number of licenses allowed

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 513

Which of the following would BEST determine whether a post implementation review (PIR) performed by the project management office (PMO) was effective?

- A. The review was performed by an external provider.
- B. Management approved the PIR report.
- C. Lessons learned were implemented.
- D. Project outcomes have been realized.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 514

Using swipe cards to limit employee access to restricted areas requires implementing which additional control?

- A. Physical sign-in of all employees for access to restricted areas
- B. Initial escort of all new hires by a current employee
- C. Periodic review of access profiles by management

D. Employee-access criteria determined on the basis of IS experience

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 515

An accounts receivable data entry routine prevents the entry of the same customer with different account numbers. Which of the following is the BEST way to test if this programmed control is effective?

- A. Compare source code against authorized software.
- B. Implement a computer-assisted audit technique (CAAT).
- C. Attempt to create a duplicate customer.
- D. Review a sorted customer list for duplicates.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 516

When reviewing user access to an application containing sensitive company data, which of the following should be the GREATEST concern with regard to segregation of duties?

- A. The help desk performs application backups.
- B. The application programmer performs quality assurance functions.
- C. The network administrator performs security administrator functions.
- D. The database administrator performs system analyst functions

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 517

Which of the following would be the MOST effective method for detecting duplicate payments?

- A. Enciphering and deciphering the message digest
- B. Reviewing sequence numbers and time stamps for each transaction
- C. Assessing payment history for reasonableness and approval
- D. Using a cryptographic hashing algorithm

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 518

Which of the following sampling methods is the BEST approach for drawing conclusions based on frequency of occurrence?

- A. Attribute sampling
- B. Monetary estimation sampling
- C. Stratified sampling
- D. Difference estimation sampling

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 519

What is the purpose of using a write blocker during the acquisition phase of a digital forensics investigation?

- A. To preserve chain of custody
- B. To protect against self-destruct utilities
- C. To prevent the activation of installed malware
- D. To prevent evidence alteration

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 520

Which of the following is the BEST indicator of a mature quality management system (QMS)?

- A. Projects are showing continuous improvement.
- B. Continuous improvement has been integrated into business processes.
- C. End users are satisfied with the outcome of IT projects.
- D. Most IT projects have been completed on time and within budget.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 521

Which of the following key performance indicators (KPIs) provides the BEST indication of a security awareness campaign's effectiveness?

- A. Reduced average time for incident resolution
- B. Percentage of attendees passing the awareness quiz
- C. Decrease in the number of help desk calls
- D. Increase in the number of reported security incidents

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 522

Which of the following is the BEST indicator that an application system's agreed-upon level of service has been met?

- A. Bandwidth usage logs
- B. Transaction response time
- C. CPU utilization reports
- D. Security incident reports

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 523

Which of the following is the BEST way to ensure enterprise architectural objectives are aligned with business and technology objectives?

- A. Identify dependencies between current and future state technologies.
- B. Optimize technology investments with business requirements.
- C. Adopt industry-approved architecture standards and best practices.
- D. Identify business stakeholder responsibilities for IT projects.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 524

Which of the following BEST facilitates the ability to efficiently allocate time, effort, and resources to address security incidents?

- A. Incident classification
- B. Incident definition
- C. Incident escalation
- D. Incident monitoring

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 525

Which of the following is the PRIMARY responsibility of an organization's IT steering committee?

- A. Reporting on key performance measures
- B. Communicating strategic goals to IT project teams
- C. Conducting peer reviews of other organizations
- D. Identifying new technological threats

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 526

Which of the following BEST provides audit management with a view of potential performance improvements within the organization's IS audit function?

- A. Post-audit quality reviews
- B. Auditor independence checklists
- C. Auditor performance reviews
- D. Quality management policies

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 527

Which of the following is the BEST way to detect potentially fraudulent purchases where an employee can approve a receipt of an item or service that the employee also procured?

- A. Require staff training on entering purchase orders into the enterprise resource planning (ERP) system.
- B. Require receipts to be entered against purchase orders by someone other than the buyer.
- C. Require that invoices can only be paid when matched with purchase orders.
- D. Require purchase orders to originate from the same individual with designated authority.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 528

Which of the following would MOST effectively detect a condition where an employee assigned to an operations role could perform system administrator functions?

- A. User access review
- B. System review
- C. Business process review
- D. Entitlement design review

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 529

Which of the following indicates the HIGHEST level of maturity for an organization's information systems internal control environment?

- A. Controls are regularly evaluated using a formally documented process.
- B. Controls are adequately documented and control exceptions are captured.
- C. The operation of controls depends on employee knowledge.
- D. Operational effectiveness is evaluated upon management request.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 530

Which of the following IT service management activities is MOST likely to help with identifying the root cause of repeated instances of network latency?

- A. Incident management
- B. Problem management
- C. Change management
- D. Configuration management

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 531

Which of the following BEST helps to ensure that all relevant data within an organization is added to a data warehouse during deployment?

- A. Data migration
- B. Architecture review
- C. Project planning
- D. Data mining

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 532

Which of the following should be the MOST important consideration in IT portfolio management?

- A. Aligning IT portfolio processes with corporate objectives
- B. Selecting IT investment projects that align with corporate strategy
- C. Increasing the budget and resources allocated for IT investments
- D. Determining the opportunity cost of IT investment projects

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 533

Which of the following is the PRIMARY objective of baselining the IT control environment?

- A. Define process and control ownership.
- B. Ensure IT security strategy and policies are effective.
- C. Align IT strategy with business strategy.
- D. Detect control deviations.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 534

Which of the following should be considered when examining fire suppression systems as part of a data center

environmental controls review?

- A. Maintenance procedures
- B. Onsite replacement availability
- C. Insurance coverage
- D. Installation manuals

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 535

Which of the following would provide the BEST assurance that an organization's backup media is adequate in the case of a disaster?

- A. Scheduled maintenance of the backup device
- B. Regular recovery of production systems in a test environment
- C. Scheduled read/write tests of the backup media
- D. Regular review of backup logs to ensure that all data from the production environment is included

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 536

Which of the following should be the FIRST step in the incident response process for a suspected breach?

- A. Inform potentially affected customers of the security breach.
- B. Notify business management of the security breach.
- C. Engage a third party to independently evaluate the alerted breach.
- D. Research the validity of the alerted breach.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 537

An IS auditor finds that a required security patch was not installed on a critical server for more than 6 months.

The NEXT course of action should be to:

- A. determine the root cause of the delay.
- B. review patch management procedures.
- C. request the patch be installed as soon as possible.
- D. notify senior management of audit findings.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 538

Which of the following is the BEST method to maintain an audit trail of changes made to the source code of a program?

- A. Standardize file naming conventions.
- B. Utilize automated version control.
- C. Document details on a change register.
- D. Embed details within source code.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 539

In which of the following cloud service models does the user organization have the GREATEST control over the accuracy of configuration items in its configuration management database (CMDB)?

- A. Database as a Service (DbaaS)
- B. Software as a Service (SaaS)
- C. Platform as a Service (PaaS)
- D. Infrastructure as a Service (IaaS)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 540

Which of the following controls is MOST effective in detecting spam?

- A. Denying transmission control protocol (TCP) connections in the mail server
- B. Refusing Internet protocol (IP) connections at the router
- C. Registering the recipient with keepers of spam lists
- D. Using heuristic filters based on the content of the message

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 541

Which of the following tools are MOST helpful for benchmarking an existing IT capability?

- A. Prior IS audit reports
- B. IT maturity models
- C. Risk assessments
- D. IT balanced scorecards

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 542

Which of the following documents would be MOST useful in detecting a weakness in segregation of duties?

- A. Entity-relationship diagram
- B. Process flowchart
- C. Data flow diagram
- D. Systems flowchart

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 543

Which of the following test approaches would utilize data analytics to validate customer authentication controls for banking transactions?

- A. Review transactions completed for one period that have blank customer identification fields.
- B. Attempt to complete a monetary transaction and leave the customer identification fields blank.
- C. Review the business requirements document for customer identification requirements.
- D. Evaluate configuration settings for transactions requiring customer identification.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 544

The purpose of data migration testing is to validate data:

- A. availability.
- B. retention.
- C. completeness.
- D. confidentiality.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 545

Which of the following is the BEST method to assess the adequacy of security awareness in an organization?

- A. Confirming a security awareness program exists
- B. Interviewing employees about security responsibility
- C. Administering security survey questionnaires
- D. Observing employee security behaviors

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 546

An organization uses a web server hosting critical applications. Which of the following would represent the HIGHEST risk regarding the availability and integrity of the web server?

- A. Inadequate rotation of backups
- B. Not disabling the server's external drives
- C. Not applying program fixes on a regular basis
- D. Placing the web server in the DMZ

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 547

Which of the following tools is MOST helpful in estimating budgets for tasks within a large IT business application project?

- A. Balanced scorecard
- B. Gantt chart
- C. Function point analysis (FPA)
- D. Critical path methodology (CPM)

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 548

The MAIN objective of incident management is to:

- A. have an external computer security incident response team assess damage.
- B. permit the incident to go on and follow the trail back to the beginning.
- C. test for readiness to respond when facing an incident.
- D. keep the business going while the response is occurring.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 549

An organization is moving its on-site application servers to a service provider that operates a virtualized environment shared by multiple customers. Which of the following is the MOST significant risk to the organization?

- A. Account hacking from other clients
- B. Competing workloads from other clients
- C. Service provider access to organizational data
- D. Service provider limiting the right to audit

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 550

During a post-implementation review, which of the following is the BEST evidence that user requirements have been met?

- A. Help desk incident tickets
- B. End-user documentation
- C. Operator error logs
- D. User acceptance testing sign-offs

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 551

The application systems quality assurance (QA) function should:

- A. assist programmers in designing and developing applications.
- B. design and develop quality applications by employing system development methodology.
- C. compare programs to approved system changes.
- D. ensure adherence of programs to standards.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 552

During a post-implementation review, a step in determining whether a project met user requirements is to review the:

- A. integrity of key calculations.
- B. change requests initiated after go-live.
- C. completeness of user documentation.
- D. effectiveness of user training.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 553

Which of the following reports can MOST effectively be used to analyze a systems performance problem?

- A. Synchronization report
- B. Console log
- C. Utilization report
- D. Database usage log

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 554

The PRIMARY objective of parallel testing an application is to confirm that:

- A. the results of calculations in the new system are as accurate as the old system.
- B. system response times in the new system are better than the old system.
- C. the costs of running the new system are the same as running the old system.
- D. new system processing times are similar to those of the old system.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 555

Which of the following areas are the MOST likely cause of an application producing several erroneous reports?

- A. A deficiency in user acceptance testing
- B. A deficiency in patch management
- C. A deficiency in IT resource allocation
- D. A deficiency in database administration

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 556

Which of the following is the BEST sampling method to use when estimating the rate of occurrence of a specific quality in a population?

- A. Attribute sampling
- B. Stop-or-go sampling
- C. Statistical sampling
- D. Discovery sampling

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 557

Which of the following is the BEST way to reduce the risk of vulnerabilities during the rapid deployment of container-based applications to a hybrid cloud?

- A. Conduct a post-deployment security audit to identify vulnerabilities.
- B. Conduct security auditing during the development life cycle.
- C. Review a sample of historical production changes to identify abnormalities.

D. Review development and operations (DevOps) policies and procedures.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 558

Which of the following is the BEST evidence of the maturity of an organization's information security program?

- A. The number of reported incidents has increased.
- B. The information security department actively monitors security operations.
- C. The number of reported incidents has decreased.
- D. IT security staff implements strict technical security controls.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 559

Which of the following types of controls would be MOST important to implement when digitizing human resource (HR) records?

- A. Change management controls
- B. Software development controls
- C. Project management controls
- D. Access management controls

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 560

Senior management has allocated funding to each of the organization's divisions to address information security vulnerabilities. The funding is based on each division's technology budget from the previous fiscal year. Which of the following should be of GREATEST concern to the information security manager?

- A. Redundant controls may be implemented across divisions
- B. Information security governance could be decentralized by divisions
- C. Areas of highest risk may not be adequately prioritized for treatment
- D. Return on investment may be inconsistently reported to senior management

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 561

Which of the following provides the BEST assurance that security policies are applied across business operations?

- A. Organizational standards are required to be formally accepted.
- B. Organizational standards are enforced by technical controls.
- C. Organizational standards are included in awareness training.
- D. Organizational standards are documented in operational procedures.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 562

What should be a security manager's PRIMARY objective in the event of a security incident?

- A. Identify the source of the breach and how it was perpetrated.
- B. Contain the threat and restore operations in a timely manner.
- C. Ensure that normal operations are not disrupted.
- D. Identify lapses in operational control effectiveness.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 563

Which of the following is the BEST indication that an information security program is effective?

- A. The number of reported and confirmed security incidents has increased after awareness training.
- B. The security awareness program was developed following industry best practices.
- C. The security team has performed a risk assessment to understand the organization's risk appetite.
- D. The security team is knowledgeable and uses the best available tools.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 564

Which of the following would be of GREATEST concern to an IS auditor reviewing an organization's security incident handling procedures?

- A. Annual tabletop exercises are performed instead of functional incident response exercises.
- B. Roles for computer emergency response team (CERT) members have not been formally documented.
- C. Guidelines for prioritizing incidents have not been identified.
- D. Workstation antivirus software alerts are not regularly reviewed.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 565

An organization has suffered a number of incidents in which USB flash drives with sensitive data have been lost. Which of the following would be MOST effective in preventing loss of sensitive data?

- A. Modifying the disciplinary policy to be more stringent
- B. Implementing a check-in/check-out process for USB flash drives
- C. Issuing encrypted USB flash drives to staff
- D. Increasing the frequency of security awareness training

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 566

Which of the following backup schemes is the BEST option when storage media is limited?

- A. Virtual backup
- B. Real-time backup
- C. Differential backup
- D. Full backup

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 567

Management has decided to include a compliance manager in the approval process for a new business that may require changes to the IT infrastructure. Which of the following is the GREATEST benefit of this approach?

- A. Security breach incidents can be identified in early stages.
- B. Regulatory risk exposures can be identified before they materialize.
- C. Fewer reviews are needed when updating the IT compliance process.
- D. Process accountabilities to external stakeholders are improved.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 568

The prioritization of incident response actions should be PRIMARILY based on which of the following?

- A. Scope of disaster
- B. Business impact
- C. Availability of personnel
- D. Escalation process

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 569

In the review of a feasibility study for an IS acquisition, the MOST important step is to:

- A. determine whether the cost-benefits are achievable.
- B. ensure that a contingency plan is in place should the project fail.
- C. ensure that the right to audit the vendor has been considered.
- D. determine whether security and control requirements have been specified.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 570

Which of the following is a passive attack on a network?

- A. Message service interruption
- B. Message modification
- C. Traffic analysis
- D. Sequence analysis

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 571

Which of the following is the MAIN purpose of an information security management system?

- A. To enhance the impact of reports used to monitor information security incidents
- B. To reduce the frequency and impact of information security incidents
- C. To identify and eliminate the root causes of information security incidents
- D. To keep information security policies and procedures up-to-date

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 572

Which of the following would be an INAPPROPRIATE activity for a network administrator?

- A. Analyzing network security incidents
- B. Prioritizing traffic between subnets
- C. Modifying a router configuration
- D. Modifying router log files

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 573

There is a concern that a salesperson may download an organization's full customer list from the Software as a Service (SaaS) when leaving to work for a competitor. Which of the following would BEST help to identify this type of incident?

- A. Monitor applications logs
- B. Disable remote access to the application
- C. Implement a web application firewall
- D. Implement an intrusion detection system (IDS)

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 574

Which of the following is the MOST important incident management consideration for an organization subscribing to a cloud service?

- A. Decision on the classification of cloud-hosted data
- B. Expertise of personnel providing incident response
- C. Implementation of a SIEM in the organization
- D. An agreement on the definition of a security incident

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 575

Which of the following would be MOST useful to an information security manager when conducting a post-incident review of an attack?

- A. Details from intrusion detection system logs
- B. Method of operation used by the attacker
- C. Cost of the attack to the organization
- D. Location of the attacker

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 576

An information security manager is preparing an incident response plan. Which of the following is the MOST important consideration when responding to an incident involving sensitive customer data?

- A. The assignment of a forensics teams
- B. The ability to recover from the incident in a timely manner
- C. Following defined post-incident review procedures
- D. The ability to obtain incident information in a timely manner

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 577

An organization that has outsourced its incident management capabilities just discovered a significant privacy breach by an unknown attacker. Which of the following is the MOST important action of the security manager?

- A. Follow the outsourcer's response plan
- B. Refer to the organization's response plan
- C. Notify the outsourcer of the privacy breach
- D. Alert the appropriate law enforcement authorities

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 578

The effectiveness of an incident response team will be GREATEST when:

- A. the incident response process is updated based on lessons learned
- B. incidents are identified using a security information and event monitoring (SIEM) system
- C. the incident response team members are trained security personnel
- D. the incident response team meets on a regular basis to review log files

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 579

An external penetration test identified a serious security vulnerability in a critical business application. Before reporting the vulnerability to senior management, the information security manager's BEST course of action should be to:

- A. determine the potential impact with the business owner
- B. initiate the incident response process
- C. block access to the vulnerable business application
- D. report the vulnerability to IT for remediation

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 580

When conducting a post-incident review, the GREATEST benefit of collecting mean time to resolution (MTTR) data is the ability to:

- A. reduce the costs of future preventive controls
- B. provide metrics for reporting to senior management
- C. verify compliance with the service level agreement (SLA)
- D. learn of potential areas of improvement

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 581

When developing an incident response plan, the information manager should:

- A. allow IT to decide which systems can be removed from the infrastructure
- B. include response scenarios that have been approved previously by business management
- C. require IT to invoke the business continuity plan
- D. determine recovery time objectives (RTOs)

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 582

Which of the following should be done FIRST when handling multiple confirmed incidents raised at the same time?

- A. Categorize incidents by the value of the affected asset.
- B. Inform senior management.
- C. Update the business impact assessment.
- D. Activate the business continuity plan.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 583

Which of the following is the BEST indication of a successful information security culture?

- A. Penetration testing is done regularly and findings remediated.
- B. End users know how to identify and report incidents.
- C. Individuals are given access based on job functions.
- D. The budget allocated for information security is sufficient.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 584

Which of the following is MOST influential when defining disaster recovery strategies?

- A. Existing server redundancies
- B. Maximum tolerable downtime
- C. Data classification scheme
- D. Annual loss expectancy

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 585

Which of the following should be of MOST concern to an IS auditor reviewing an organization's disaster recovery plan (DRP)?

- A. The responsibility for declaring a disaster is not identified.
- B. The disaster recovery steps are not detailed.
- C. The CIO has not signed off on the DRP.
- D. Copies of the DRP are not kept in a secure offsite location.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 586

Which of the following is MOST important for an IS auditor to verify during a disaster recovery audit?

- A. Disaster recovery tests are carried out.
- B. Regular backups are made and stored offsite.
- C. The disaster recovery plan is updated on a regular basis.
- D. Media are stored in fireproof cabinets.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 587

An IS auditor observes that an organization's critical IT systems have experienced several failures throughout the year. Which of the following is the BEST recommendation?

- A. Perform a disaster recovery test.
- B. Perform a root cause analysis.
- C. Contract for a hot site.
- D. Implement redundant systems.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 588

Of the following procedures for testing a disaster recovery plan (DRP), which should be used MOST frequently?

- A. Unannounced shutdown of the primary computing facility.
- B. Review of documented backup and recovery procedures
- C. Testing at a secondary site using offsite data backups
- D. Preplanned shutdown of the computing facility during an off-peak period

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 589
When reviewing a disaster recovery plan (DRP), an IS auditor should examine the:

- A. access to the computer site by backup staff.
- B. offsite data file storage.
- C. uninterruptible power supply (UPS).
- D. fire-fighting equipment.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 590
Since data storage of a critical business application is on a redundant array of inexpensive disks (RAID), backups are not considered essential. The IS auditor should recommend proper backups because RAID:

- A. relies on proper maintenance.
- B. cannot offer protection against disk corruption.
- C. cannot recover from a natural disaster.
- D. disks cannot be hot-swapped for quick recovery.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 591
Which of the following would be the GREATEST concern when an organization's disaster recovery strategy utilizes a cold site?

- A. The lack of electrical power connections
- B. The lack of networking infrastructure
- C. The lack of appropriate environmental controls
- D. The lack of hardware components availability

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 592
Which of the following would be MOST helpful in ensuring security procedures are followed by employees in a multinational organization?

- A. Security architecture review
- B. Regular clean desk reviews
- C. Comprehensive end-user training
- D. Regular policy updates by management

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 593
Which of the following BEST describes the relationship between vulnerability scanning and penetration testing?

- A. For entities with regulatory drivers the two tests must be the same.
- B. Both are labor-intensive in preparation, planning and execution.
- C. Both utilize a risk-based analysis that considers treats scenarios.
- D. The scope of both is determined primarily by the likelihood of exploitation.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 594
An IS audit manager finds that data manipulation logic developed by the audit analytics team leads to incorrect conclusions. This inaccurate logic is MOST likely an indication of which of the following?

- A. Incompatibility between data volume and analytics processing capacity.

- B. Poor security controls that grant inappropriate access to analysis produced.
- C. The team's poor understanding of the business process being analyzed.
- D. Poor change controls over data sets collected from the business.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 595

Which of the following would be the MOST effective method to identify high risk areas in the business to be included in the audit plan?

- A. Validate current risk from prior internal audit findings.
- B. Review industry reports to identify common risk areas.
- C. Engage with management to understand the business.
- D. Review external audit reports of the business.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 596

Which of the following approaches would utilize data analytics to facilitate the testing of a new account creation process?

- A. Review the business requirements document for date of birth field requirements.
- B. Review new account applications submitted in the past month for invalid dates of birth.
- C. Evaluate configuration settings for the date of birth field requirements.
- D. Attempt to submit new account applications with invalid dates of birth.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 597

Which of the following would be the PRIMARY benefit of replacing physical keys with an electronic badge system for access to a data center?

- A. Increasing accountability
- B. Maintaining compliance
- C. Tracking employee work hours
- D. Increasing reliability

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 598

Outsourcing the development of business systems is MOST likely to result in the loss of:

- A. control over strategic direction.
- B. accountability for end products.
- C. in-house competencies.
- D. responsibility for IT security.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 599

Overall responsibility for approving logical access rights to information assets should reside with the:

- A. data and systems owners.
- B. systems delivery and operations group.
- C. security administrator.
- D. systems administrator.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 600

In a complex IS environment, which of the following tasks should be performed by the data owner?

- A. Perform technical database maintenance.
- B. Perform data restoration when necessary.
- C. Review data classifications periodically.
- D. Test the validity of backup data.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 601

An organization uses electronic funds transfer (EFT) to pay its vendors. Which of the following should be an IS auditor's MAIN focus while reviewing controls in the accounts payable application?

- A. Changes to the vendor master file
- B. Volume of transactions
- C. Amount of disbursements
- D. Frequency of transactions

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 602

Which of the following analytical methods would be MOST useful when trying to identify groups with similar behavior or characteristics in a large population?

- A. Classification
- B. Correlation analysis
- C. Deviation detection
- D. Clustering

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 603

Which of the following is the BEST way to determine the effectiveness of a recently installed intrusion detection system (IDS)?

- A. Implement access control.
- B. Conduct attack simulation.
- C. Review audit logs.
- D. Inspect IDS configuration.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 604

Which of the following is the MOST important activity to undertake to avoid rework later in a project?

- A. Control review
- B. Risk assessment
- C. Acceptance testing
- D. Phase review

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 605

Which of the following is the GREATEST risk posed by denial-of-service attacks?

- A. Confidential information leakage
- B. Loss of integrity and corruption of databases
- C. Loss of reputation and business
- D. Unauthorized access to the systems

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 606

Which of the following would BEST indicate the effectiveness of a security awareness training program?

- A. Increased number of employees completing training
- B. Employee satisfaction with training
- C. Reduced unintentional violations
- D. Results of third-party social engineering tests.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 607

A grants management system is used to calculate grant payments. Once per day, a batch interface extracts grant amounts and payee details from this system for import into the finance system so payments can be made overnight. Which of the following controls provides the GREATEST assurance of the accuracy and completeness of the imported payments?

- A. Performing monthly bank reconciliations in a timely manner
- B. Restricting access to the grants and finance systems
- C. Reviewing transaction logs for anomalies
- D. Reconciling data from both systems

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 608

Requiring that passwords contain a combination of numeric and alphabetic characters is MOST effective against which type of attack?

- A. Denial of service
- B. Dictionary
- C. Social engineering
- D. Programmed

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 609

The BEST way to prevent fraudulent payments is to implement segregation of duties between payment processing and:

- A. requisition creation.
- B. vendor setup.
- C. payment approval.
- D. check creation.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 610

Which of the following is the BEST approach to verify that internal help desk procedures are executed in compliance with policies?

- A. Benchmark help desk procedures.
- B. Interview end users.
- C. Test a sample of closed tickets.
- D. Evaluate help desk call metrics.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 611

When replacing a critical software application, which of the following provides for the LOWEST risk of interruption to business processes?

- A. Parallel implementation
- B. Pilot implementation
- C. Incremental implementation
- D. Big-bang implementation

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 612

The MOST critical security weakness of a packet level firewall is that it can be circumvented by:

- A. using a dictionary attack of encrypted passwords.
- B. changing the source address on incoming packets.
- C. intercepting packets and viewing passwords sent in clear text.
- D. deciphering the signature information of the packets.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 613

Which of the following BEST contributes to the successful management of security incidents?

- A. Tested controls
- B. Established procedures
- C. Established policies
- D. Current technologies

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 614

Which of the following is the BEST indicator of an effective employee information security program?

- A. Increased management support for security
- B. More efficient and effective incident handling
- C. Increased detection and reporting of incidents
- D. Reduced operational cost of security

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 615

Of the following, who should the security manager consult FIRST when determining the severity level of a security incident involving a third-party vendor?

- A. IT process owners
- B. Business partners
- C. Risk manager
- D. Business process owners

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 616

An external security audit risk has reported multiple instances of control noncompliance. Which of the following would be MOST important for the information security manager to communicate to senior management?

- A. The impact of noncompliance on the organization's risk profile
- B. An accountability report to initiate remediation activities
- C. A plan for mitigating the risk due to noncompliance
- D. Control owner responses based on a root cause analysis

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 617

Which of the following is the MOST important outcome of effective risk treatment?

- A. Timely reporting of incidents
- B. Elimination of risk
- C. Implementation of corrective actions
- D. Reduced cost of maintaining controls

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 618

To overcome the perception that security is a hindrance to business activities, it is important for an information security manager to:

- A. rely on senior management to enforce security
- B. promote the relevance and contribution of security
- C. reiterate the necessity of security
- D. focus on compliance

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 619

When developing an escalation process for an incident response plan, the information security manager should PRIMARLY consider the:

- A. affected stakeholders
- B. availability of technical resources
- C. incident response team
- D. media coverage

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 620

Which of the following is the MOST important reason for logging firewall activity?

- A. Intrusion detection
- B. Auditing purposes
- C. Firewall tuning
- D. Incident investigation

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 621

The PRIMARY purpose of a security information and event management (SIEM) system is to:

- A. identify potential incidents
- B. provide status of incidents
- C. resolve incidents
- D. track ongoing incidents

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 622

Which of the following is MOST likely to reduce the effectiveness of a signature-based intrusion detection system (IDS)?

- A. The activities being monitored deviate from what is considered normal.
- B. The environment is complex.
- C. The pattern of normal behavior changes quickly and dramatically.
- D. The information regarding monitored activities becomes stale.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 623

Information security awareness programs are MOST effective when they are:

- A. customized for each target audience
- B. conducted at employee orientation
- C. reinforced by computer-based training
- D. sponsored by senior management

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 624

An information security manager has discovered a potential security breach in a server that supports a critical business process. Which of the following should be the information security manager's FIRST course of action?

- A. Validate that there has been an incident
- B. Notify the business process owner
- C. Shut down the server in an organized manner
- D. Inform senior management of the incident

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 625

Which of the following is the MOST important outcome of testing incident response plans?

- A. Internal procedures are improved.
- B. An action plan is available for senior management.
- C. Staff is educated about current threats.
- D. Areas requiring investment are identified.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 626

What should be the MAIN goal of an organization's incident response plan?

- A. Keep stakeholders notified of incident status.
- B. Enable appropriate response according to criticality.
- C. Correlate incidents from different systems.
- D. Identify the root cause of the incident.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 627

An organization has purchased a security information and event management (SIEM) tool. Which of the following would be MOST important to consider before implementation?

- A. The contract with the SIEM vendor
- B. Controls to be monitored
- C. Available technical support
- D. Reporting capabilities

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 628

A client/server configuration will:

- A. optimize system performance by having a server on a front-end and clients on a host
- B. enhance system performance through the separation of front-end and back-end processes
- C. keep track of all the clients using the IS facilities of a service organization
- D. limit the clients and servers' relationship by limiting the IS facilities to a single hardware system

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 629

Which of the following would BEST ensure the confidentiality of sensitive data during transmission?

- A. Restricting the recipient through destination IP addresses
- B. Sending data over public networks using Secure Sockets Layer (SSL)
- C. Password protecting data over virtual local area networks (VLAN)
- D. Sending data through proxy servers

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 630

Which of the following is the GREATEST risk of cloud computing?

- A. Reduced performance
- B. Disclosure of data
- C. Lack of scalability
- D. Inflexibility

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 631

In an IT organization where many responsibilities are shared, which of the following would be the BEST control for detecting unauthorized data changes?

- A. Data changes are independently reviewed by another group.

- B. Users are required to periodically rotate responsibilities.
- C. Segregation of duties conflicts are periodically reviewed.
- D. Data changes are logged in an outside application.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 632

Which of the following is a substantive test procedure?

- A. Using audit software to verify the total of an accounts receivable file
- B. Observing that user IDs and passwords are required to sign on to the online system
- C. Test of invoice calculation process
- D. Verifying that appropriate approvals are documented in a sample of program changes

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 633

Which of the following is an advantage of decentralized security administration?

- A. Greater integrity
- B. Faster turnaround
- C. More uniformity
- D. Better-trained administrators

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 634

An IS auditor notes that several recent incidents related to server overload were not anticipated early enough by IT operations to prevent outages. Which of the following is the auditor's BEST recommendation?

- A. Update the IT operations balanced scorecard.
- B. Improve training for IT operations personnel.
- C. Re-evaluate key performance indicators (KPIs).
- D. Purchase additional server hardware.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 635

An IS audit of help desk operations reveals that a number of similar issues have recently been reported to the help desk, but incident details have not been tracked. Which of the following is the MOST significant risk in this situation?

- A. The help desk may not be meeting agreed-upon service levels.
- B. The help desk may not be able to perform root cause analysis.
- C. The help desk may lack resources to investigate incidents.
- D. The help desk may not respond to incidents in a timely manner.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 636

Using development and operations (DevOps) processes, an organization's IT department has automated the process of replacing application programming interfaces (APIs) in production with new versions. Which of the following controls would BEST reduce the risk of vulnerabilities in this situations?

- A. Review API change requests to ensure appropriate authorization exists
- B. Conduct API security testing prior to release into production
- C. Examine API log files to determine when changes occur in production
- D. Review an up-to-date inventory of APIs in production for completeness

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 637

An IT department is unaware of spreadsheets and databases that have been created by business end users to support their respective operations. Which of the following is the GREATEST risk in this situation?

- A. End-user solutions may not have proper documentation.

- B. End-user developed systems may duplicate data.
- C. End-user solutions may not be protected by IT general controls.
- D. End-user developed systems may be inefficient.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 638

Which of the following observations should be of MOST concern to an IS auditor evaluating an IT security team's incident handling practices?

- A. The team's scope covers any nonstandard operation of IT services within the organization.
- B. The prioritization of incidents is not done through a standardized process.
- C. Defined acceptable ranges for incident resolution are not established.
- D. Unresolved incidents are escalated based on criteria set by the organization's CIO.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 639

Which of the following is the BEST indication that an organization's security incident and event monitoring (SIEM) capability is operating effectively?

- A. Security event logging is centralized.
- B. Security event logging policies are defined.
- C. Security event logging is enabled for individual applications.
- D. Security event logging is correlated across multiple applications.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 640

Which of the following is an example of a corrective control?

- A. Restoring system information from data backups
- B. Utilizing processes that enforce segregation of duties
- C. Generating automated batch job failure notifications
- D. Employing only qualified personnel to execute tasks

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 641

Which of the following is the BEST way to mitigate the risk associated with a document storage application that has a syncing feature that could allow malware to spread to other machines in the network?

- A. An audit should be conducted to detect shadow data and shadow IT in the network.
- B. User behavior modeling and analysis should be performed to discover anomalies in user behavior.
- C. Content inspection technologies should be used to scan files for sensitive data.
- D. All files should be scanned when they are uploaded to and downloaded from the application.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 642

After an employee termination, a network account was removed, but the application account remained active. To keep this issue from recurring, which of the following is the BEST recommendation?

- A. Integrate application accounts with network single sign-on.
- B. Perform periodic access reviews.
- C. Leverage shared accounts for the application.
- D. Retrain system administration staff.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 643

Which of the following incident management practices would BEST facilitate rapid resolution and reduce downtime from unplanned interruptions?

- A. Ensuring the service desk has access to catalogs of known errors
- B. Ensuring IT systems are monitored on a continual basis

- C. Ensuring incidents with unknown root causes are escalated
- D. Ensuring the service desk is trained on issue resolution

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 644

Which of the following would BEST help to ensure that an incident receives attention from appropriate personnel in a timely manner?

- A. Implementing incident escalation procedures
- B. Broadcasting an emergency message
- C. Completing the incident management log
- D. Requiring a dedicated incident response team

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 645

What is an IS auditor's BEST recommendation to strengthen security guidelines in order to prevent data leakage from the use of smart devices?

- A. Include usage restrictions for smart devices in the security procedures.
- B. Require employees to formally acknowledge security procedures.
- C. Review the access logs to the organization's sensitive data in a timely manner.
- D. Enforce strong security settings on smart devices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 646

Which type of risk has materialized when an internal IS auditor discovers an issue that external auditors missed due to improperly applied audit procedures?

- A. Detection risk
- B. Inherent risk
- C. Sampling risk
- D. Control risk

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 647

Following a security breach, an IS auditor finds an organization's transport layer security (TLS) certificate is compromised. Which of the following would be the auditor's BEST recommendation to the system administrator?

- A. Disable and retrieve the key from escrow.
- B. Revoke and regenerate TLS certificates.
- C. Repurchase the key from the certification authority (CA).
- D. Re-issue TLS certificates with a new effective date.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 648

Which of the following BEST facilitates scalability objectives for an organization that anticipates a significant increase in web traffic?

- A. Load balancers
- B. Distributive allocation of servers
- C. Failover clusters
- D. Redundant array of inexpensive disks (RAID)

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 649

Which of the following is the BEST way to detect system security breaches?

- A. Ensuring maximum interoperability among systems throughout the organization
- B. Performing intrusion tests on a regular basis
- C. Conducting frequent vulnerability scans
- D. Conducting continuous monitoring with an automated system security tool

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 650

Backups will MOST effectively minimize a disruptive incident's impact on a business if they are:

- A. stored on write-once read-many media.
- B. performed by automated backup software on a fixed schedule.
- C. scheduled according to the service delivery objectives.
- D. taken according to recovery point objectives (RPOs)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 651

An organization has outsourced its help desk services. Which of the following would be MOST useful in evaluating the quality of the service provider?

- A. Benchmark results against industry peers
- B. Percentage of cases reopened
- C. End-user satisfaction survey results
- D. Average waiting time in queue

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 652

Which of the following is the BEST justification for an organization's decision to go with active-active application clustering instead of active-passive?

- A. High availability is a priority.
- B. Increased demand on network latency is a concern.
- C. Load balancing is a priority.
- D. The relevant application is not set up to be cluster-aware.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 653

Which of the following tasks would cause the GREATEST segregation of duties (SoD) concern if performed by

the person who reconciles the organization's device inventory?

- A. Tracking devices used for spare parts
- B. Approving the issuing of devices
- C. Creating the device policy
- D. Issuing devices to employees

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 654

Which of the following audit procedures would provide the BEST assurance that an application program is functioning as designed?

- A. Reviewing program documentation
- B. Confirming accounts
- C. Interviewing business management
- D. Using a continuous auditing module

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 655

Which of the following would BEST indicate a mature information security program within an organization?

- A. A decrease in the cost of the IT security program
- B. A decrease in the average time to remediate vulnerabilities
- C. A decrease in time from incident identification to containment
- D. A decrease in the number of attempted attacks per month

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 656

Segregation of duties would be compromised if:

- A. operations staff modified batch schedules.
- B. application programmers moved programs into production.
- C. application programmers accessed test data.
- D. database administrators (DBAs) modified the structure of user tables.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 657

Which of the following stakeholders is accountable for control evaluations during a control self-assessment (CSA)?

- A. Chief internal auditor
- B. Enterprise risk management
- C. Quality assurance management
- D. Department managers

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 658

Which of the following approaches provides the BEST assurance and user confidence when an organization migrates data to a more complex enterprise resource planning (ERP) system?

- A. Pilot testing
- B. User acceptance testing
- C. Phased changeover
- D. Parallel processing

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 659

Which is a clear indicator that an organization's IS strategic planning is inadequate?

- A. Lack of infrastructure service performance measurement
- B. Disjoined decision making about infrastructure
- C. Resource conflicts between infrastructure projects
- D. Infrastructure services provided by multiple vendors

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 660

An organization has fully outsourced its email functions to a third-party cloud service provider. Which of the following is the MOST important responsibility of the IT unit supporting this function?

- A. Reassessing service provider contracts annually
- B. Monitoring service provider performance
- C. Reviewing independent audit reports of the service provider
- D. Approving timely service provider payments

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 661

In the risk assessment process, which of the following should be identified FIRST?

- A. Threats
- B. Vulnerabilities
- C. Assets
- D. Impact

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 662

Which of the following is the MOST important consideration when sampling is required to validate management's remediation of audit findings?

- A. Whether management approves the sampling methodology to be used
- B. Whether the sampling techniques align with industry standards
- C. Whether audit team members performing the sampling are adequately trained on the chosen sampling techniques
- D. Whether an adequate amount of time has passed to produce a representative population for testing

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 663

Which of the following is the BEST evidence of senior management review of IT performance?

- A. Key IT performance indicators
- B. IT tactical plans
- C. Executive committee meeting minutes
- D. Balanced scorecard

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 664

A senior IS auditor suspects that a PC may have been used to perpetrate a fraud in a finance department. The auditor should FIRST report this suspicion to:

- A. audit management
- B. the audit committee
- C. the police
- D. auditee line management

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 665

An IS auditor follows up on a recent security incident and finds the incident response was not adequate. Which of the following findings should be considered MOST critical?

- A. The attack could not be traced back to the originating person.
- B. The security weakness facilitating the attack was not identified.
- C. Appropriate response documentation was not maintained.
- D. The attack was not automatically blocked by the intrusion detection system (IDS).

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 666

Which of the following would provide the MOST useful information for evaluating whether network availability is meeting the performance objectives set by management?

- A. Capability maturity model
- B. Balanced scorecard
- C. IT value analysis
- D. Gap analysis

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 667

Of the following, who is BEST suited to establish an organization's risk tolerance?

- A. Senior leadership
- B. Chief audit executive (CAE)
- C. Information system owner
- D. Information security officer

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 668

Which of the following is MOST essential to quality management?

- A. Adherence to a globally recognized quality standard
- B. Application of statistical process control methods
- C. Commitment on the part of executive management
- D. Teamwork by all representatives of the quality group

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 669

Which of the following roles is BEST suited to determine information classification?

- A. Data custodian
- B. Data owner
- C. Privacy officer
- D. Information security manager

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 670

Which of the following control techniques BEST ensures the integrity of system interface transmissions?

- A. Reasonableness check
- B. Validity check
- C. Completeness check
- D. Parity check

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support <https://www.infosecrain.com/blog/cisa-domain-3-information-systems-acquisition-development-and-implementation-part-7/>

QUESTION 671

To address issues related to privileged users identified in an IS audit, management implemented a security information and event management (SIEM) system. Which type of control is in place?

- A. Directive
- B. Corrective
- C. Detective
- D. Preventive

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support <https://www.isaca.org/resources/isaca-journal/issues/2015/volume-5/cybersecurity-detective-controls/monitoring-to-identify-and-respond-to-threats>

QUESTION 672

Which type of control is in place when an organization requires new employees to complete training on applicable privacy and data protection regulations?

- A. Directive control
- B. Detective control
- C. Corrective control
- D. Preventive control

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support <https://www.isaca.org/resources/isaca-journal/issues/2020/volume-2/aligning-coso-and-privacy-frameworks-to-manage-privacy-in-a-post-gdpr-world>

QUESTION 673

Which of the following is the MOST important process to ensure planned IT system changes are completed in an efficient manner?

- A. Configuration management
- B. Demand management
- C. Release management
- D. Incident management

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 674

Which of the following will BEST help to ensure that an in-house application in the production environment is current?

- A. Version control procedures
- B. Quality assurance (QA)
- C. Production access control
- D. Change management

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 675

During a review of IT service desk practices, an IS auditor notes that help desk personnel are spending more time fulfilling user requests for password resets than resolving critical incidents. Which of the following recommendations to IT management would BEST address this situation?

- A. Calculate the age of incident tickets and alert senior IT personnel when they exceed service level agreements (SLAs).
- B. Provide annual password management training to end users to reduce the number of instances requiring . password resets
- C. Incentivize service desk personnel to close incidents within agreed service levels .
- D. Implement a self-service solution and redirect users to access frequently requested services.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 676

Which of the following is the MAIN benefit of using data analytics when testing the effectiveness of controls?

- A. The full population can be tested.
- B. Analytics can be applied to any type of control.
- C. The demand for IS auditors is reduced over time.
- D. Analytics remove the need to focus on areas of higher risk.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support <https://www.isaca.org/resources/isaca-journal/issues/2017/volume-2/how-analytics-will-transform-internal-audit>

QUESTION 677

When measuring the effectiveness of a security awareness program, the MOST helpful key performance indicator (KPI) is the number of:

- A. employees who have signed the information security policy.
- B. employees passing a phishing exercise.
- C. security incidents detected by tools.
- D. employees attending security awareness training.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 678

Which of the following technologies has the SMALLEST maximum range for data transmission between devices?

- A. Near-field communication (NFC)
- B. Wi-Fi
- C. Bluetooth
- D. Long-term evolution (LTE)

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 679

During the post-implementation review of an application that was implemented six months ago, which of the following would be MOST helpful in determining whether the application meets business requirements?

- A. Project closure report and lessons-learned documents from the project management office (PMO)
- B. User acceptance testing (UAT) results and sign-off from users on meeting business requirements
- C. Difference between approved budget and actual project expenditures determined post implementation
- D. Comparison between expected benefits from the business case and actual benefits after implementation

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 680

Which of the following provides the BEST evidence of the effectiveness of an organization's audit quality management procedures?

- A. Number of audits completed within the annual audit plan
- B. Quality of auditor performance reviews
- C. Quality of independent review scores
- D. Number of resources dedicated to quality control procedures

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 681

Which of the following is the GREATEST benefit of utilizing data analytics?

- A. Improved communication with management due to more confidence with data results
- B. Higher-quality audit evidence due to more representative audit sampling
- C. Better risk assessments due to the identification of anomalies and trends
- D. Expedient audit planning due to early identification of problem areas and incomplete data

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 682

Which of the following is MOST appropriate for measuring a batch processing application's system performance over time?

- A. Throughput
- B. Idle time
- C. System utilization
- D. Uptime

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 683

Regression testing should be used during a system development project to ensure that:

- A. errors have not been introduced to the system during modification.
- B. the test plan is based on an analysis of the impact of past testing.
- C. system testing will address high-probability errors.
- D. the results of testing are statistically valid.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 684

During an operational audit of a biometric system used to control physical access, which of the following should be of GREATEST concern to an IS auditor?

- A. False positives
- B. Lack of biometric training
- C. User acceptance of biometrics
- D. False negatives

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 685

Which of the following is the BEST indication that an information security program is aligned with organizational objectives?

- A. The information security steering committee sets organizational security priorities.
- B. Senior management conducts regular reviews of information security policies.
- C. Information security processes are in place throughout the system development life cycle (SDLC).
- D. Risk is managed to within organizational tolerances.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 686

Which of the following is the MOST effective accuracy control for entry of a valid numeric part number?

- A. Hash totals
- B. Comparison to historical order pattern
- C. Self-checking digit
- D. Online review of description

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 687

An IS auditor is conducting a post-implementation review of an enterprise resource planning (ERP) system. End users indicated concerns with the accuracy of critical automatic calculations made by the system. The auditor's FIRST course of action should be to:

- A. verify completeness of user acceptance testing (UAT).
- B. verify results to determine validity of user concerns.
- C. review initial business requirements.
- D. review recent changes to the system

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 688

Which of the following is the GREATEST concern associated with a high number of IT policy exceptions approved by management?

- A. The exceptions may result in noncompliance.
- B. The exceptions may negatively impact process efficiency.
- C. The exceptions are likely to continue indefinitely.
- D. The exceptions may elevate the level of operational risk.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 689

The use of which of the following would BEST enhance a process improvement program?

- A. Project management methodologies
- B. Capability maturity models
- C. Balanced scorecard
- D. Model-based design notations

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 690

An organization maintains an inventory of the IT applications used by its staff. Which of the following would pose the GREATEST concern with regard to the quality of the inventory data?

- A. Inventory data is available on and downloadable from the corporate intranet.
- B. The application owner and contact information fields are not required to be completed.
- C. The inventory does not contain a formal risk ranking for all the IT applications.
- D. The organization has not established a formal recertification process for the inventory data.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 691

Of the following, who are the MOST appropriate staff for ensuring the alignment of user authorization tables with approved authorization forms?

- A. IT managers
- B. System owners
- C. Database administrators (DBAs)
- D. Security administrators

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 692

Which of the following is the BEST compensating control when segregation of duties is lacking in a small IS department?

- A. Transaction log review
- B. User awareness training
- C. Mandatory holidays
- D. Background check

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 693
Which of the following encryption methods offers the BEST wireless security?

- A. Wired equivalent privacy (WEP)
- B. Secure Sockets Layer (SSL)
- C. Data encryption standard (DES)
- D. Wi-Fi Protected Access 2 (WPA2)

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 694
Which of the following is the BEST way to mitigate the risk associated with technology obsolescence?

- A. Make provisions in the budgets for potential upgrades
- B. Create a technology watch team that evaluates emerging trends
- C. Invest in current technology
- D. Create tactical and strategic IS plans

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 695
Which of the following is the GREATEST risk associated with conducting penetration testing on a business- critical application production environment?

- A. Data integrity may become compromised
- B. This type of testing may not adhere to audit standards
- C. System owners may not be informed in advance
- D. Results may differ from those obtained in the test environment

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 696
An organization is disposing of a system containing sensitive data and has deleted all files from the disk. An IS auditor should be concerned because:

- A. deleted data cannot easily be retrieved.
- B. deleting the files logically does not overwrite the files' physical data.
- C. backup copies of files were not deleted as well.
- D. deleting all files separately is not as efficient as formatting the hard disk.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 697
Batch processes running in multiple countries are merged to one batch job to be executed in a single data center. Which of the following is the GREATEST concern with this approach?

- A. The job execution approval process at the regional level may be compromised
- B. The knowledge base maintained by current staff may be lost
- C. Change management may become highly complex after job integration
- D. Restart of the batch job after disruption may impair the integrity of databases

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 698
Which of the following is the MAJOR advantage of automating internal controls?

- A. To help identify transactions with no segregation of duties
- B. To enable the review of large value transactions

- C. To efficiently test large volumes of data
- D. To assist in performing analytical reviews

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 699

A data breach has occurred due to malware. Which of the following should be the FIRST course of action?

- A. Notify customers of the breach
- B. Notify the cyber insurance company
- C. Shut down the affected systems
- D. Quarantine the impacted systems

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 700

An IS audit found that malware entered the organization through a spreadsheet macro, and the auditor recommended that spreadsheet macros be disabled. All macros were disabled except those needed by the finance team for reporting purposes. Which of the following is the auditor's BEST course of action?

- A. Close the recommendation, as most of the risk has been mitigated
- B. Advise management to disable the spreadsheet macros for the finance users
- C. Recommend alternate reporting methods that do not use spreadsheet macros
- D. Escalate the issue to the audit committee

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 701

In a 24/7 processing environment, a database contains several privileged application accounts with passwords set to "never expire". Which of the following recommendations would BEST address the risk with minimal disruption to the business?

- A. Modify the access management policy to make allowances for application accounts
- B. Introduce database access monitoring into the environment
- C. Modify applications to no longer require direct access to the database
- D. Schedule downtime to implement password changes

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 702

Which of the following is MOST important when duties in a small organization cannot be appropriately segregated?

- A. Exception reporting
- B. Variance reporting
- C. Independent reviews
- D. Audit trail

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 703

An IS auditor has found that an organization is unable to add new servers on demand in a cost-efficient manner. Which of the following is the auditor's BEST recommendation?

- A. Upgrade hardware to newer technology
- B. Build a virtual environment
- C. Hire temporary contract workers for the IT function
- D. Increase the capacity of existing systems

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 704

Which of the following metrics would be MOST useful to an IS auditor when assessing the resilience of an application programming interface (API)?

- A. Number of developers adopting the API for their applications
- B. Number of patches released within a time interval for the API

- C. Number of API calls expected versus actually received within a time interval
- D. Number of defects logged during development compared to other APIs

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 705

Which of the following is the BEST use of a balanced scorecard when evaluating IT performance?

- A. Monitoring alignment of IT with the rest of the organization
- B. Determining compliance with relevant regulatory requirements
- C. Monitoring alignment of the IT project portfolio to budget
- D. Evaluating implementation of the business strategy

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 706

A checksum is classified as which type of control?

- A. Corrective control
- B. Detective control
- C. Preventive control
- D. Administrative control

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 707

Which of the following is the GREATEST risk associated with vulnerability scanning tools used to identify security weaknesses?

- A. False positives
- B. False negatives
- C. Use of open source tools
- D. Outdated signatures for detection

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 708

Which of the following controls is BEST implemented through system configuration?

- A. Network user accounts for temporary workers expire after 90 days
- B. Financial data in key reports is traced to source systems for completeness and accuracy
- C. Application user access is reviewed every 180 days for appropriateness
- D. Computer operations personnel initiate batch processing jobs daily

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 709

An audit has identified that business units have purchased cloud-based applications without IT's support. What is the GREATEST risk associated with this situation?

- A. The application purchases did not follow procurement policy.
- B. The applications may not reasonably protect data.
- C. The applications could be modified without advanced notice.
- D. The applications are not included in business continuity plans (BCPs).

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 710

Which of the following is MOST important for an IS auditor to review when evaluating the accuracy of a spreadsheet that contains several macros?

- A. Formulas within macros
- B. Encryption of the spreadsheet
- C. Version history
- D. Reconciliation of key calculations

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 711

An algorithm in an email program analyzes traffic to quarantine emails identified as spam. The algorithm in the program is BEST characterized as which type of control?

- A. Corrective
- B. Detective
- C. Directive
- D. Preventive

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 712

Due to system limitations, segregation of duties (SoD) cannot be enforced in an accounts payable system. Which of the following is the IS auditor's BEST recommendation for a compensating control?

- A. Require written authorization for all payment transactions
- B. Reconcile payment transactions with invoices
- C. Restrict payment authorization to senior staff members
- D. Review payment transaction history

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 713

An organization is migrating its human resources (HR) application to an infrastructure as a Service (IaaS) model in a private cloud. Who is PRIMARILY responsible for the security configurations of the deployed application's operating system?

- A. The organization
- B. The operating system vendor
- C. The cloud provider
- D. The cloud provider's external auditor

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 714

Which of the following is MOST important for an IS auditor to verify during a disaster recovery audit?

- A. Roles and responsibilities are documented
- B. Regular backups are made and stored offsite.
- C. The disaster recovery plan (DRP) is updated on a regular basis.
- D. Tabletop disaster recovery tests are conducted.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 715

The use of control totals reduces the risk of:

- A. incomplete processing.
- B. improper backup.
- C. posting to the wrong record.
- D. improper authorization.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 716

For an organization which uses a VoIP telephony system exclusively, the GREATEST concern associated with leaving a connected telephone in an unmonitored public area is the possibility of:

- A. connectivity issues when used with an analog local exchange carrier
- B. unauthorized use leading to theft of services and financial loss
- C. network compromise due to the introduction of malware
- D. theft or destruction of an expensive piece of electronic equipment

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 717

Which of the following provides nonrepudiation in an electronic communication session without confidentiality?

- A. Message encryption
- B. Log-on ID and password
- C. Certification authority
- D. Digital signature

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 718

Which of the following is the GREATEST security risk associated with data migration from a legacy human resources (HR) system to a cloud-based system?

- A. System performance may be impacted by the migration.
- B. Records past their retention period may not be migrated to the new system.
- C. Data from the source and target system may have different data formats.
- D. Data from the source and target system may be intercepted.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 719

When responding to an ongoing denial of service (DoS) attack, an organization's FIRST course of action should be to:

- A. restore service
- B. minimize impact
- C. analyze the attack path
- D. investigate damage

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 720

Which of the following is the GREATEST risk when relying on reports generated by end-user computing?

- A. Data may be inaccurate
- B. Reports may not work efficiently
- C. Reports may not be timely
- D. Historical data may not be available

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 721

A disk management system's PRIMARY function is to:

- A. monitor disk accesses for analytical review
- B. deny access to disk resident data files
- C. provide data on efficient disk usage
- D. provide the method of control for disk usage

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 722

Which of the following is a detective control?

- A. Procedures for authorizing transactions
- B. Echo checks in telecommunications
- C. A router rule restricting a service
- D. Programmed edit checks

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 723

Which of the following is the GREATEST threat to Voice-over Internet Protocol (VoIP) related to privacy release?

- A. Incorrect routing
- B. Eavesdropping
- C. Call recording
- D. Denial of service

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 724

The MOST effective control to detect fraud inside an organization's network, is to:

- A. implement an intrusion detection system (IDS)
- B. apply two-factor authentication
- C. review access logs
- D. segregate duties

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 725

Which of the following is the GREATEST risk of single sign-on?

- A. Password carelessness by one user may render the entire infrastructure vulnerable
- B. Integration of single sign-on with the rest of the infrastructure is complicated
- C. It is a single point of failure for an enterprise access control process
- D. One administrator maintains the single sign-on solutions without segregation of duty

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 726

An IT department has given a vendor remote access to the internal network for troubleshooting network performance problems. After discovering the remote activity during a firewall log review, which of the following is the BEST course of action for an information security manager?

- A. Revoke the access.
- B. Review the related service level agreement (SLA).
- C. Determine the level of access granted.
- D. Declare a security incident.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 727

Which of the following is the BEST defense against a brute force attack?

- A. Discretionary access control
- B. Intruder detection lockout
- C. Mandatory access control
- D. Time-of-day restrictions

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 728

Which of the following is the GREATEST security threat when an organization allows remote access to a virtual private network (VPN)?

- A. Client logins are subject to replay attack.
- B. VPN traffic could be sniffed and captured.
- C. Compromised VPN clients could impact the network.
- D. Attackers could compromise the VPN gateway.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 729

The PRIMARY benefit of a centralized time server is that it:

- A. reduces individual time-of-day requests by client applications
- B. is required by password synchronization programs
- C. allows decentralized logs to be kept in synchronization
- D. decreases the likelihood of an unrecoverable systems failure

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 730

An information security manager has observed multiple exceptions for a number of different security controls. Which of the following should be the information security manager's FIRST course of action?

- A. Design mitigating controls for the exceptions.
- B. Prioritize the risk and implement treatment options.
- C. Inform respective risk owners of the impact of exceptions.
- D. Report the noncompliance to the board of directors.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 731

An employee uses a personal mobile device to access corporate data and email, but also allows friends to use it as a mobile hotspot for Internet access when not at work. The information security manager is concerned this situation may expose confidential data. The manager's FIRST step should be to:

- A. update the mobile device usage standards to address the issue and communicate to all employees
- B. activate the incident response plan to mitigate the impact and stop the compromise
- C. review the associated risks to determine if additional controls are needed
- D. implement additional security controls that will mitigate the situation and then reassess risks

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 732

Senior management has approved employees working off-site by using a virtual private network (VPN) connection. It is MOST important for the information security manager to periodically:

- A. review firewall configuration
- B. review the security policy
- C. perform a cost-benefit analysis
- D. perform a risk assessment

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 733

The BEST way to avoid session hijacking is to use:

- A. a reverse lookup
- B. a secure protocol
- C. a firewall
- D. strong password controls

Correct Answer: B

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 734

Which of the following outsourced services has the GREATEST need for security monitoring?

- A. Web site hosting
- B. Application development
- C. Virtual private network (VPN) services
- D. Enterprise infrastructure

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 735

Identify the INCORRECT statement related to network performance below?

- A. Bandwidth - Bandwidth commonly measured in bits/second is the maximum rate that information can be transferred
- B. Latency - Latency the actual rate that information is transferred
- C. Jitter - Jitter variation in the time of arrival at the receiver of the information
- D. Error Rate - Error rate the number of corrupted bits expressed as a percentage or fraction of the total sent

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support The word INCORRECT is the keyword used within the question. You need to find out a statement which is incorrectly describe about network performance. Throughput the actual rate that information is transferred and Latency is the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any nodes the information traverses

For your exam you should know below information about Network performance:

Network performance refers to measurement of service quality of a telecommunications product as seen by the customer.

The following list gives examples of network performance measures for a circuit-switched network and one type of packet-switched network (ATM):

Circuit-switched networks: In circuit switched networks, network performance is synonymous with the grade of service. The number of rejected calls is a measure of how well the network is performing under heavy traffic loads. Other types of performance measures can include noise, echo and so on.

ATM: In an Asynchronous Transfer Mode (ATM) network, performance can be measured by line rate, quality of service (QoS), data throughput, connect time, stability, technology, modulation technique and modem enhancements.

There are many different ways to measure the performance of a network, as each network is different in nature and design. Performance can also be modeled instead of measured; one example of this is using state transition diagrams to model queuing performance in a circuit-switched network. These diagrams allow the network planner to analyze how the network will perform in each state, ensuring that the network will be optimally designed.

The following measures are often considered important:

Bandwidth - Bandwidth is commonly measured in bits/second is the maximum rate that information can be transferred

Throughput - Throughput is the actual rate that information is transferred Latency - Latency is the delay between the sender and the receiver decoding it, this is mainly a function of the signals travel time, and processing time at any nodes the information traverses Jitter - Jitter is the variation in the time of arrival at the receiver of the information Error Rate - Error rate is the number of corrupted bits expressed as a percentage or fraction of the total sent

The following answers are incorrect:

The other options correctly describe network performance parameters.
CISA review manual 2014 page number 275

QUESTION 736

To ensure efficient and economic use of limited resources in supporting a local area network (LAN) infrastructure, it is advisable to:

- A. periodically rotate vendors to obtain the best price-to-performance ratio.
- B. standardize on a limited number of device models and software applications.
- C. quickly upgrade to the latest hardware and software versions to take advantage of new features.
- D. recommend a variety of products so that user effectiveness and flexibility can be maximized.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 737

An organization uses two data centers. Which of the following would BEST address the organization's need for high resiliency?

- A. The data centers act as mirrored sites.
- B. Each data center is recoverable via tape backups.
- C. A hot site is used for the second site.
- D. There is data replication across the data centers.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 738

Performance monitoring tools report that servers are significantly below their planned utilization. Which of the following would be the BEST recommendation?

- A. Consolidate physical servers.
- B. Review the capacity plan.
- C. Deploy load balancing.
- D. Reconfigure server settings.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 739

Which of the following occurs during the issues management process for a system development project?

- A. Contingency planning
- B. Impact assessment

- C. Configuration management
- D. Help desk management

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 740

A security administrator should have read-only access for which of the following?

- A. Router configuration
- B. Password policy
- C. Security logs
- D. Services/daemons configuration

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 741

Which of the following should be the PRIMARY consideration for IT management when selecting a new information security tool that monitors suspicious file access patterns?

- A. Integration with existing architecture
- B. Ease of support and troubleshooting
- C. Data correlation and visualization capabilities
- D. Ability to contribute to key performance indicator data

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 742

Which of the following is the MOST critical characteristic of a biometric system?

- A. Registration time
- B. Throughput rate
- C. Accuracy
- D. Ease of use

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 743

Which of the following will BEST ensure that a proper cutoff has been established to reinstate transactions and records to their condition just prior to a computer system failure?

- A. Maintaining system console logs in electronic format
- B. Ensuring bisynchronous capabilities on all transmission lines
- C. Using a database management system (DBMS) to dynamically back-out partially processed transactions
- D. Rotating backup copies of transaction files offsite

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 744

Which of the following is the MOST likely cause of a successful firewall penetration?

- A. Use of a Trojan to bypass the firewall
- B. Loophole in firewall vendor's code
- C. Virus infection
- D. Firewall misconfiguration by the administrator

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 745

Intrusion detection systems (IDSs) can:

- A. substitute for a firewall.
- B. compensate for weak authentication mechanisms.
- C. conduct investigations of attacks from within the network.

D. provide information to enhance the security infrastructure.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 746

Which of the following is the GREATEST concern with conducting penetration testing on an internally developed application in the production environment?

- A. The testing could create application availability issues.
- B. The testing may identify only known operating system vulnerabilities.
- C. The issues identified during the testing may require significant remediation efforts.
- D. Internal security staff may not be qualified to conduct application penetration testing.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 747

What is the MOST important business concern when an organization is about to migrate a mission-critical application to a virtual environment?

- A. The organization's experience with virtual applications
- B. Adequacy of the fallback procedures
- C. Confidentiality of network traffic
- D. Adequacy of the virtual architecture

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 748

Which of the following is the PRIMARY reason for database optimization in an environment with a high volume of transactions?

- A. Improving availability
- B. Maintaining integrity
- C. Preventing data leakage
- D. Improving performance

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 749

Which of the following tasks should be performed during an organization's business continuity plan (BCP) test?

- A. Evaluate the security at the offsite facility.
- B. Review the coverage of insurance.
- C. Assess the critical information retrieval capability.
- D. Review the alternate processing site contract.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 750

A potential risk of executing a program on an Internet site is that it may:

- A. install executable code on the computer.
- B. lack version control, which may result in the use of an older program.
- C. overwrite system files with older versions.
- D. be browser-dependent, and therefore abort.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 751

Which of the following would be considered the BEST compensating control to use when an emergency process, rather than the established control procedures, is used for database changes?

- A. Using an emergency user account with the access to make changes to the database
- B. Using the administrator's own account to make out-of-hours changes
- C. Logging detailed before-and-after images for later review by the administrator
- D. Logging user's ID and change details for later review by the administrator

Correct Answer: C
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 752
What is the purpose of a hypervisor?

- A. Monitoring the performance of virtual machines
- B. Cloning virtual machines
- C. Deploying settings to multiple machines simultaneously
- D. Running the virtual machine environment

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 753
Which of the following is the PRIMARY advantage of single sign-on (SSO)?

- A. Improves system performance
- B. Ensures good password practices
- C. Improves security
- D. Reduces administrative workload.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 754
An accounting department uses a spreadsheet to calculate sensitive financial transactions. Which of the following is the MOST important control for maintaining the security of data in the spreadsheet?

- A. There is a reconciliation process between the spreadsheet and the finance system.
- B. The spreadsheet is locked down to avoid inadvertent changes.
- C. A separate copy of the spreadsheet is routinely backed up.
- D. Access to the spreadsheet is given only to those who require access.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 755
Which of the following BEST ensures that only authorized software is moved into a production environment?

- A. Restricting read/write access to production code to computer programmers only
- B. Assigning programming managers to transfer tested programs to production
- C. A librarian compiling source code into production after independent testing
- D. Requiring programming staff to move tested code into production

Correct Answer: B
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 756
Which of the following is the BEST way to help ensure the security of privacy-related data stored by an organization?

- A. Encrypt personally identifiable information (PII).
- B. Publish the data classification scheme.
- C. Inform data owners of the purpose of collecting information.
- D. Classify privacy-related data as confidential.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Information System Operations, Maintenance and Support

QUESTION 757
Which of the following controls is MOST appropriate against brute force attacks at login?

- A. Storing password files using one-way encryption
- B. Locking the account after three invalid passwords
- C. Storing passwords under a one-way hash function
- D. Increasing the minimum password length to 10 characters

Correct Answer: B
Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 758

An organization has performance metrics to track how well IT resources are being used, but there has been little progress on meeting the organization's goals. Which of the following would be MOST helpful to determine the underlying reason?

- A. Conducting a root cause analysis
- B. Re-evaluating organizational goals
- C. Re-evaluating key performance indicators (KPIs)
- D. Conducting a business impact analysis (BIA)

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 759

Which of the following concerns is BEST addressed by securing production source libraries?

- A. Production source and object libraries may not be synchronized.
- B. Unauthorized changes can be moved into production.
- C. Programs are not approved before production source libraries are updated.
- D. Changes are applied to the wrong version of production source libraries.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 760

Which of the following is MOST important for successful incident response?

- A. The timelessness of attack recognition
- B. The ability to trace the source of the attack
- C. The quantity of data logged by the attack control tools
- D. Blocking the attack route immediately

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 761

Which of the following is the MOST effective control in an organization to mitigate the risk of insider misuse of personal devices?

- A. Security risk assessments
- B. Periodic vulnerability scanning
- C. Security awareness training
- D. Comprehensive procedures on data security

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 762

Which of the following security testing techniques is MOST effective in discovering unknown malicious attacks?

- A. Vulnerability testing
- B. Reverse engineering
- C. Penetration testing
- D. Sandboxing

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 763

Which of the following hardware upgrades would BEST enhance the capability of a web server to accommodate a significant increase in web traffic?

- A. Multicore CPUs
- B. Solid state drives
- C. Additional flash memory
- D. Cloud architecture

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Information System Operations, Maintenance and Support

QUESTION 764

An organization has recently converted its infrastructure to a virtualized environment. The GREATEST benefit related to disaster recovery is that virtualized servers:

- A. reduce the time it takes to successfully create backups.
- B. decrease the recovery time objective (RTO).
- C. eliminate the manpower necessary to restore the server.
- D. can be recreated on similar hardware faster than restoring from backups.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 765

Which of the following would help to ensure the completeness of batch file transfers?

- A. Input controls
- B. Self-checking digits
- C. Hash totals
- D. Parity check

Correct Answer: C

Explanation

Explanation/Reference:

Section: Information System Operations, Maintenance and Support

QUESTION 766

The sender of a public key would be authenticated by a:

- A. certificate authority.
- B. digital signature.
- C. digital certificate.
- D. registration authority.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A digital certificate is an electronic document that declares a public key holder is who the holder claims to be. The certificates do handle data authentication as they are used to determine who sent a particular message. A certificate authority issues the digital certificates, and distributes, generates and manages public keys. A digital signature is used to ensure integrity of the message being sent and solve the nonrepudiation issue of message origination. The registration authority would perform most of the administrative tasks of a certificate authority, i.e., registration of the users of a digital signature plus authenticating the information that is put in the digital certificate.

QUESTION 767

An IS auditor finds that conference rooms have active network ports. Which of the following is MOST important to ensure?

- A. The corporate network is using an intrusion prevention system (IPS)
- B. This part of the network is isolated from the corporate network
- C. A single sign-on has been implemented in the corporate network
- D. Antivirus software is in place to protect the corporate network

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If the conference rooms have access to the corporate network, unauthorized users may be able to connect to the corporate network; therefore, both networks should be isolated either via a firewall or being physically separated. An IPS would detect possible attacks, but only after they have occurred. A single sign-on would ease authentication management. Antivirus software would reduce the impact of possible viruses; however, unauthorized users would still be able to access the corporate network, which is the biggest risk.

QUESTION 768

What is the BEST action to prevent loss of data integrity or confidentiality in the case of an e-commerce application running on a LAN, processing electronic fund transfers (EFT) and orders?

- A. Using virtual private network (VPN) tunnels for data transfer
- B. Enabling data encryption within the application
- C. Auditing the access control to the network
- D. Logging all changes to access lists

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The best way to ensure confidentiality and integrity of data is to encrypt it using virtual private network (VPN) tunnels. This is the most common and convenient way to encrypt the data traveling over the network. Data encryption within the application is less efficient than VPN. The other options are good practices, but they do not directly prevent the loss of data integrity and confidentiality during communication through a network.

QUESTION 769

When conducting a penetration test of an IT system, an organization should be MOST concerned with:

- A. the confidentiality of the report.

- B. finding all possible weaknesses on the system.
- C. restoring all systems to the original state.
- D. logging all changes made to the production system.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

All suggested items should be considered by the system owner before agreeing to penetration tests, but the most important task is to be able to restore all systems to their original state. Information that is created and/or stored on the tested systems should be removed from these systems. If for some reason, at the end of the penetration test, this is not possible, all files (with their location) should be identified in the technical report so that the client's technical staff will be able to remove these after the report has been received.

QUESTION 770

Which of the following penetration tests would MOST effectively evaluate incident handling and response capabilities of an organization?

- A. Targeted testing
- B. External testing
- C. internal testing
- D. Double-blind testing

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In a double-blind test, the administrator and security staff are not aware of the test, which will result in an assessment of the incident handling and response capability in an organization. In targeted, external, and internal testing, the system administrator and security staff are aware of the tests since they are informed before the start of the tests.

QUESTION 771

When protecting an organization's IT systems, which of the following is normally the next line of defense after the network firewall has been compromised?

- A. Personal firewall
- B. Antivirus programs
- C. Intrusion detection system (IDS)
- D. Virtual local area network (VLAN) configuration

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An intrusion detection system (IDS) would be the next line of defense after the firewall. It would detect anomalies in the network/server activity and try to detect the perpetrator. Antivirus programs, personal firewalls and VIAN configurations would be later in the line of defense.

QUESTION 772

In wireless communication, which of the following controls allows the device receiving the communications to verify that the received communications have not been altered in transit?

- A. Device authentication and data origin authentication
- B. Wireless intrusion detection (IDS) and prevention systems (IPS)
- C. The use of cryptographic hashes
- D. Packet headers and trailers

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Calculating cryptographic hashes for wireless communications allows the device receiving the communications to verify that the received communications have not been altered in transit. This prevents masquerading and message modification attacks. Device authentication and data origin authentication is not the correct answer since authenticating wireless endpoints to each other prevents man-in-the-middle attacks and masquerading. Wireless IDS/IPSS is not the correct answer since wireless IDS/IPS have the ability to detect misconfigured devices and rogue devices, and detect and possibly stop certain types of attacks. Packet headers and trailers alone do not ensure that the content has not been altered.

QUESTION 773

An organization is planning to replace its wired networks with wireless networks. Which of the following would BEST secure the wireless network from unauthorized access?

- A. Implement Wired Equivalent Privacy (WEP)
- B. Permit access to only authorized Media Access Control (MAC) addresses
- C. Disable open broadcast of service set identifiers (SSID)
- D. Implement Wi-Fi Protected Access (WPA) 2

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Wi-Fi Protected Access (WPA) 2 implements most of the requirements of the IEEE 802.11i standard. The

Advanced Encryption Standard (AES) used in WPA2 provides better security. Also, WPA2 supports both the Extensible Authentication Protocol and the preshared secret key authentication model. Implementing Wired Equivalent Privacy (WEP) is incorrect since it can be cracked within minutes. WEP uses a static key which has to be communicated to all authorized users, thus management is difficult. Also, there is a greater vulnerability if the static key is not changed at regular intervals. The practice of allowing access based on Media Access Control (MAC) is not a solution since MAC addresses can be spoofed by attackers to gain access to the network. Disabling open broadcast of service set identifiers (SSID) is not the correct answer as they cannot handle access control.

QUESTION 774

An IS auditor is reviewing a software-based configuration. Which of the following represents the GREATEST vulnerability? The firewall software:

- A. is configured with an implicit deny rule as the last rule in the rule base.
- B. is installed on an operating system with default settings.
- C. has been configured with rules permitting or denying access to systems or networks.
- D. is configured as a virtual private network (VPN) endpoint.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Default settings are often published and provide an intruder with predictable configuration information, which allows easier system compromise. To mitigate this risk, firewall software should be installed on a system using a hardened operating system that has limited functionality, providing only the services necessary to support the firewall software. Choices A, C and D are normal or best practices for firewall configurations.

QUESTION 775

The GREATEST risk posed by an improperly implemented intrusion prevention system (IPS) is:

- A. that there will be too many alerts for system administrators to verify.
- B. decreased network performance due to IPS traffic.
- C. the blocking of critical systems or services due to false triggers.
- D. reliance on specialized expertise within the IT organization.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An intrusion prevention system (IPS) prevents a connection or service based on how it is programmed to react to specific incidents. If the packets are coming from a spoofed address and the IPS is triggered based on previously defined behavior, it may block the service or connection of a critical internal system. The other choices are risks that are not as severe as blocking critical systems or services due to false triggers.

QUESTION 776

The MOST effective control for reducing the risk related to phishing is:

- A. centralized monitoring of systems.
- B. including signatures for phishing in antivirus software.
- C. publishing the policy on antiphishing on the intranet.
- D. security training for all users.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Phishing is a type of e-mail attack that attempts to convince a user that the originator is genuine, with the intention of obtaining information. Phishing is an example of a social engineering attack. Any social engineering type of attack can best be controlled through security and awareness training.

QUESTION 777

When reviewing a digital certificate verification process, which of the following findings represents the MOST significant risk?

- A. There is no registration authority (RA) for reporting key compromises
- B. The certificate revocation list (CRL) is not current.
- C. Digital certificates contain a public key that is used to encrypt messages and verify digital signatures.
- D. Subscribers report key compromises to the certificate authority (CA).

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If the certificate revocation list (CRL) is not current, there could be a digital certificate that is not revoked that could be used for unauthorized or fraudulent activities. The certificate authority (CA) can assume the responsibility if there is no registration authority (RA). Digital certificates containing a public key that is used to encrypt messages and verifying digital signatures is not a risk. Subscribers reporting key compromises to the CA is not a risk since reporting this to the CA enables the CA to take appropriate action.

QUESTION 778

When using a digital signature, the message digest is computed:

- A. only by the sender.
- B. only by the receiver.
- C. by both the sender and the receiver.
- D. by the certificate authority (CA).

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A digital signature is an electronic identification of a person or entity. It is created by using asymmetric encryption. To verify integrity of data, the sender uses a cryptographic hashing algorithm against the entire message to create a message digest to be sent along with the message. Upon receipt of the message, the receiver will recompute the hash using the same algorithm and compare results with what was sent to ensure the integrity of the message.

QUESTION 779

Which of the following would effectively verify the originator of a transaction?

- A. Using a secret password between the originator and the receiver

- B. Encrypting the transaction with the receiver's public key
- C. Using a portable document format (PDF) to encapsulate transaction content
- D. Digitally signing the transaction with the source's private key

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A digital signature is an electronic identification of a person, created by using a public key algorithm, to verify to a recipient the identity of the source of a transaction and the integrity of its content. Since they are a 'shared secret' between the user and the system itself, passwords are considered a weaker means of authentication. Encrypting the transaction with the recipient's public key will provide confidentiality for the information, while using a portable document format (PDF) will probe the integrity of the content but not necessarily authorship.

QUESTION 780

A perpetrator looking to gain access to and gather information about encrypted data being transmitted over the network would use:

- A. eavesdropping
- B. spoofing.
- C. traffic analysis.
- D. masquerading.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In traffic analysis, which is a passive attack, an intruder determines the nature of the traffic flow between defined hosts and through an analysis of session length, frequency and message length, and the intruder is able to guess the type of communication taking place. This typically is used when messages are encrypted and eavesdropping would not yield any meaningful results, in eavesdropping, which also is a passive attack, the intruder gathers the information flowing through the network with the intent of acquiring and releasing message contents for personal analysis or for third parties. Spoofing and masquerading are active attacks, in spoofing, a user receives an e-mail that appears to have originated from one source when it actually was sent from another source. In masquerading, the intruder presents an identity other than the original identity.

QUESTION 781

Upon receipt of the initial signed digital certificate the user will decrypt the certificate with the public key of the:

- A. registration authority (RA).
- B. certificate authority (CA).
- C. certificate repository.
- D. receiver.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A certificate authority (CA) is a network authority that issues and manages security credentials and public keys for message encryption. As a part of the public key infrastructure, a CA checks with a registration authority (RA) to verify information provided by the requestor of a digital certificate. If the RA verifies the requestor's

information, the CA can issue a certificate. The CA signs the certificate with its private key for distribution to the user. Upon receipt, the user will decrypt the certificate with the CA's public key.

QUESTION 782

IS management is considering a Voice-over Internet Protocol (VoIP) network to reduce telecommunication costs and management asked the IS auditor to comment on appropriate security controls. Which of the following security measures is MOST appropriate?

- A. Review and, where necessary, upgrade firewall capabilities
- B. Install modems to allow remote maintenance support access
- C. Create a physically distinct network to handle VoIP traffic
- D. Redirect all VoIP traffic to allow clear text logging of authentication credentials

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Firewalls used as entry points to a Voice-over Internet Protocol (VoIP) network should be VoIP- capable. VoIP network services such as H.323 introduce complexities that are likely to strain the capabilities of older firewalls. Allowing for remote support access is an important consideration. However, a virtual private network (VPN) would offer a more secure means of enabling this access than reliance on modems. Logically separating the VoIP and data network is a good idea. Options such as virtual LANS (VLANs), traffic shaping, firewalls and network address translation (NAT) combined with private IP addressing can be used; however, physically separating the networks will increase both cost and administrative complexity. Transmitting or storing clear text information, particularly sensitive information such as authentication credentials, will increase network vulnerability. When designing a VoIP network, it is important to avoid introducing any processing that will unnecessarily increase latency since this will adversely impact VoIP quality.

QUESTION 783

Which of the following intrusion detection systems (IDSs) will MOST likely generate false alarms resulting from normal network activity?

- A. Statistical-based
- B. Signature-based
- C. Neural network
- D. Host-based

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A statistical-based IDS relies on a definition of known and expected behavior of systems. Since normal network activity may at times include unexpected behavior

(e.g., a sudden massive download by multiple users), these activities will be flagged as suspicious. A signature-based IDS is limited to its predefined set of detection rules, just like a virus scanner. A neural network combines the previous two IDSs to create a hybrid and better system. Host-based is another classification of IDS. Any of the three IDSs above may be host- or network-based.

QUESTION 784

When auditing security for a data center, an IS auditor should look for the presence of a voltage regulator to ensure that the:

- A. hardware is protected against power surges.
- B. integrity is maintained if the main power is interrupted.
- C. immediate power will be available if the main power is lost.
- D. hardware is protected against long-term power fluctuations.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A voltage regulator protects against short-term power fluctuations. It normally does not protect against long-term surges, nor does it maintain the integrity if power is interrupted or lost.

QUESTION 785

Which of the following methods of suppressing a fire in a data center is the MOST effective and environmentally friendly?

- A. Halon gas
- B. Wet-pipe sprinklers
- C. Dry-pipe sprinklers
- D. Carbon dioxide gas

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Water sprinklers, with an automatic power shutoff system, are accepted as efficient because they can be set to automatic release without threat to life, and water is environmentally friendly. Sprinklers must be dry-pipe to prevent the risk of leakage. Halon is efficient and effective as it does not threaten human life and, therefore, can be set to automatic release, but it is environmentally damaging and very expensive. Water is an acceptable medium but the pipes should be empty to avoid leakage, so a full system is not a viable option. Carbon dioxide is accepted as an environmentally acceptable gas, but it is less efficient because it cannot be set to automatic release in a staffed site since it threatens life.

QUESTION 786

Which of the following is MOST efficiently protects computer equipment against short-term reductions in electrical power?

- A. Power line conditioners
- B. Surge protective devices
- C. Alternative power supplies
- D. Generators

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Power line conditioners are used to compensate for peaks and valleys in the power supply and reduce peaks in the power flow to what is needed by the machine. Any valleys are removed by power stored in the equipment. Surge protection devices protect against high-voltage bursts. Alternative power supplies are intended for computer equipment running for longer periods and are normally coupled with other devices such as an uninterruptible power supply (UPS) to compensate for the power loss until the alternate power supply

becomes available. An interruptible power supply would cause the equipment to come down whenever there was a power failure.

QUESTION 787

An IS auditor inspected a windowless room containing phone switching and networking equipment and documentation binders. The room was equipped with two handheld fire extinguishers—one filled with CO₂, the other filled with halon. Which of the following should be given the HIGHEST priority in the auditor's report?

- A. The halon extinguisher should be removed because halon has a negative impact on the atmospheric ozone layer.
- B. Both fire suppression systems present a risk of suffocation when used in a closed room.
- C. The CO₂ extinguisher should be removed, because CO₂ is ineffective for suppressing fires involving solid combustibles (paper).
- D. The documentation binders should be removed from the equipment room to reduce potential risks.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Protecting people's lives should always be of highest priority in fire suppression activities. CO₂ and halon both reduce the oxygen ratio in the atmosphere, which can induce serious personal hazards, in many countries installing or refilling halon fire suppression systems is not allowed. Although CO₂ and halon are effective and appropriate for fires involving synthetic combustibles and electrical equipment, they are nearly totally ineffective on solid combustibles (wood and paper). Although not of highest priority, removal of the documentation would probably reduce some of the risks.

QUESTION 788

Which of the following would be BEST prevented by a raised floor in the computer machine room?

- A. Damage of wires around computers and servers
- B. A power failure from static electricity
- C. Shocks from earthquakes
- D. Water flood damage.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary reason for having a raised floor is to enable power cables and data cables to be installed underneath the floor. This eliminates the safety and damage risks posed when cables are placed in a spaghetti-like fashion on an open floor. Static electricity should be avoided in the machine room; therefore, measures such as specially manufactured carpet or shoes would be more appropriate for static prevention than a raised floor. Raised floors do not address shocks from earthquakes. To address earthquakes, anti-seismic architecture would be required to establish a quake-resistant structural framework. Computer equipment needs to be protected against water. However, a raised floor would not prevent damage to the machines in the event of overhead water pipe leakage.

QUESTION 789

A penetration test performed as part of evaluating network security:

- A. provides assurance that all vulnerabilities are discovered.
- B. should be performed without warning the organization's management.
- C. exploits the existing vulnerabilities to gain unauthorized access.
- D. would not damage the information assets when performed at network perimeters.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Penetration tests are an effective method of identifying real-time risks to an information processing environment. They attempt to break into a live site in order to gain unauthorized access to a system. They do have the potential for damaging information assets or misusing information because they mimic an experienced hacker attacking a live system. On the other hand, penetration tests do not provide assurance that all vulnerabilities are discovered because they are based on a limited number of procedures. Management should provide consent for the test to avoid false alarms to IT personnel or to law enforcement bodies.

QUESTION 790

Users are issued security tokens to be used in combination with a PIN to access the corporate virtual private network (VPN). Regarding the PIN, what is the MOST important rule to be included in a security policy?

- A. Users should not leave tokens where they could be stolen
- B. Users must never keep the token in the same bag as their laptop computer
- C. Users should select a PIN that is completely random, with no repeating digits
- D. Users should never write down their PIN

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

If a user writes their PIN on a slip of paper, an individual with the token, the slip of paper, and the computer could access the corporate network. A token and the PIN is a two-factor authentication method. Access to the token is of no value without the PIN; one cannot work without the other. The PIN does not need to be random as long as it is secret.

QUESTION 791

Which of the following fire suppression systems is MOST appropriate to use in a data center environment?

- A. Wet-pipe sprinkler system
- B. Dry-pipe sprinkler system
- C. FM-200system
- D. Carbon dioxide-based fire extinguishers

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

FM-200 is safer to use than carbon dioxide. It is considered a clean agent for use in gaseous fire suppression applications. A water-based fire extinguisher is suitable when sensitive computer equipment could be damaged before the fire department personnel arrive at the site. Manual firefighting (fire extinguishers) may not provide fast enough protection for sensitive equipment (e.g., network servers).

QUESTION 792

During the review of a biometrics system operation, an IS auditor should FIRST review the stage of:

- A. enrollment.
- B. identification.
- C. verification.
- D. storage.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The users of a biometrics device must first be enrolled in the device. The device captures a physical or behavioral image of the human, identifies the unique features and uses an algorithm to convert them into a string of numbers stored as a template to be used in the matching processes.

QUESTION 793

An accuracy measure for a biometric system is:

- A. system response time.
- B. registration time.
- C. input file size.
- D. false-acceptance rate.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

For a biometric solution three main accuracy measures are used: false-rejection rate (FRR), cross-error rate (CER) and false-acceptance rate (FAR). FRR is a measure of how often valid individuals are rejected. FAR is a measure of how often invalid individuals are accepted. CER is a measure of when the false-rejection rate equals the false-acceptance rate. Choices A and B are performance measures.

QUESTION 794

What is a risk associated with attempting to control physical access to sensitive areas such as computer rooms using card keys or locks?

- A. Unauthorized individuals wait for controlled doors to open and walk in behind those authorized.
- B. The contingency plan for the organization cannot effectively test controlled access practices.
- C. Access cards, keys and pads can be easily duplicated allowing easy compromise of the control.
- D. Removing access for those who are no longer authorized is complex.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The concept of piggybacking compromises all physical control established. Choice B would be of minimal concern in a disaster recovery environment. Items in choice C are not easily duplicated. Regarding choice D, while technology is constantly changing, card keys have existed for some time and appear to be a viable option for the foreseeable future.

QUESTION 795

An organization with extremely high security requirements is evaluating the effectiveness of biometric systems. Which of the following performance indicators is MOST important?

- A. False-acceptance rate (FAR)
- B. Equal-error rate (EER)
- C. False-rejection rate (FRR)
- D. False-identification rate (FIR)

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

FAR is the frequency of accepting an unauthorized person as authorized, thereby granting access when it should be denied, in an organization with high security requirements, user annoyance with a higher FRR is less important, since it is better to deny access to an authorized individual than to grant access to an unauthorized individual. EER is the point where the FAR equals the FRR; therefore, it does not minimize the FAR. FIR is the probability that an authorized person is identified, but is assigned a false ID.

QUESTION 796

The MOST effective control for addressing the risk of piggybacking is:

- A. a single entry point with a receptionist.
- B. the use of smart cards.
- C. a biometric door lock.
- D. a deadman door.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Deadman doors are a system of using a pair of (two) doors. For the second door to operate, the first entry door must close and lock with only one person permitted in the holding area. This reduces the risk of an unauthorized person following an authorized person through a secured entry (piggybacking). The other choices are all physical controls over entry to a secure area but do not specifically address the risk of piggybacking.

QUESTION 797

The BEST overall quantitative measure of the performance of biometric control devices is:

- A. false-rejection rate.
- B. false-acceptance rate.
- C. equal-error rate.
- D. estimated-error rate.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A low equal-error rate (EER) is a combination of a low false-rejection rate and a low false- acceptance rate.

EER, expressed as a percentage, is a measure of the number of times that the false-rejection and false- acceptance rates are equal. A low EER is the measure of the more effective biometrics control device. Low false-rejection rates or low false- acceptance rates alone do not measure the efficiency of the device. Estimated-error rate is nonexistent and therefore irrelevant.

QUESTION 798

Which of the following is the MOST effective control over visitor access to a data center?

- A. Visitors are escorted.
- B. Visitor badges are required.
- C. Visitors sign in.
- D. Visitors are spot-checked by operators.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Escorting visitors will provide the best assurance that visitors have permission to access the data processing facility. Choices B and C are not reliable controls. Choice D is incorrect because visitors should be accompanied at all times while they are on the premises, not only when they are in the data processing facility.

QUESTION 799

The use of residual biometric information to gain unauthorized access is an example of which of the following attacks?

- A. Replay
- B. Brute force
- C. Cryptographic
- D. Mimic

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Residual biometric characteristics, such as fingerprints left on a biometric capture device, may be reused by an attacker to gain unauthorized access. A brute force attack involves feeding the biometric capture device numerous different biometric samples. A cryptographic attack targets the algorithm or the encrypted data, in a mimic attack, the attacker reproduces characteristics similar to those of the enrolled user, such as forging a signature or imitating a voice.

QUESTION 800

A firm is considering using biometric fingerprint identification on all PCs that access critical data. This requires:

- A. that a registration process is executed for all accredited PC users.
- B. the full elimination of the risk of a false acceptance.
- C. the usage of the fingerprint reader be accessed by a separate password.
- D. assurance that it will be impossible to gain unauthorized access to critical data.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The fingerprints of accredited users need to be read, identified and recorded, i.e., registered, before a user may operate the system from the screened PCs.

Choice B is incorrect, as the false- acceptance risk of a biometric device may be optimized, but will never be zero because this would imply an unacceptably high risk of false rejection. Choice C is incorrect, as the fingerprint device reads the token (the user's fingerprint) and does not need to be protected in itself by a password. Choice D is incorrect because the usage of biometric protection on PCs does not guarantee that other potential security weaknesses in the system may not be exploited to access protected data.

QUESTION 801

Which of the following biometrics has the highest reliability and lowest false-acceptance rate (FAR)?

- A. Palm scan
- B. Face recognition
- C. Retina scan
- D. Hand geometry

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Retina scan uses optical technology to map the capillary pattern of an eye's retina. This is highly reliable and has the lowest false-acceptance rate (FAR) among the current biometric methods. Use of palm scanning entails placing a hand on a scanner where a palm's physical characteristics are captured. Hand geometry, one of the oldest techniques, measures the physical characteristics of the user's hands and fingers from a three dimensional perspective. The palm and hand biometric techniques lack uniqueness in the geometry data. In face biometrics, a reader analyzes the images captured for general facial characteristics. Though considered a natural and friendly biometric, the main disadvantage of face recognition is the lack of uniqueness, which means that people looking alike can fool the device.

QUESTION 802

The MOST likely explanation for a successful social engineering attack is:

- A. that computers make logic errors.
- B. that people make judgment errors.
- C. the computer knowledge of the attackers.
- D. the technological sophistication of the attack method.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Humans make errors in judging others; they may trust someone when, in fact, the person is untrustworthy. Driven by logic, computers make the same error every time they execute the erroneous logic; however, this is not the basic argument in designing a social engineering attack. Generally, social engineering attacks do not require technological expertise; often, the attacker is not proficient in information technology or systems. Social engineering attacks are human-based and generally do not involve complicated technology.

QUESTION 803

The purpose of a deadman door controlling access to a computer facility is primarily to:

- A. prevent piggybacking.
- B. prevent toxic gases from entering the data center.
- C. starve a fire of oxygen.
- D. prevent an excessively rapid entry to, or exit from, the facility.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The purpose of a deadman door controlling access to a computer facility is primarily intended to prevent piggybacking. Choices B and C could be accomplished with a single self-closing door. Choice D is invalid, as a rapid exit may be necessary in some circumstances, e.g., a fire.

QUESTION 804

Which of the following is the MOST reliable form of single factor personal identification?

- A. Smart card
- B. Password
- C. Photo identification
- D. iris scan

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Since no two irises are alike, identification and verification can be done with confidence. There is no guarantee that a smart card is being used by the correct person since it can be shared, stolen or lost and found. Passwords can be shared and, if written down, carry the risk of discovery. Photo IDs can be forged or falsified.

QUESTION 805

A data center has a badge-entry system. Which of the following is MOST important to protect the computing assets in the center?

- A. Badge readers are installed in locations where tampering would be noticed
- B. The computer that controls the badge system is backed up frequently
- C. A process for promptly deactivating lost or stolen badges exists
- D. All badge entry attempts are logged

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Tampering with a badge reader cannot open the door, so this is irrelevant. Logging the entry attempts may be of limited value. The biggest risk is from unauthorized individuals who can enter the data center, whether they are employees or not. Thus, a process of deactivating lost or stolen badges is important. The configuration of the system does not change frequently, therefore frequent backup is not necessary.

QUESTION 806

Which of the following physical access controls effectively reduces the risk of piggybacking?

- A. Biometric door locks
- B. Combination door locks
- C. Deadman doors
- D. Bolting door locks

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Deadman doors use a pair of doors. For the second door to operate, the first entry door must close and lock with only one person permitted in the holding area. This effectively reduces the risk of piggybacking. An individual's unique body features such as voice, retina, fingerprint or signature activate biometric door locks; however, they do not prevent or reduce the risk of piggybacking. Combination door locks, also known as cipher locks, use a numeric key pad or dial to gain entry. They do not prevent or reduce the risk of piggybacking since unauthorized individuals may still gain access to the processing center. Bolting door locks require the traditional metal key to gain entry. Unauthorized individuals could still gain access to the processing center along with an authorized individual.

QUESTION 807

The MOST effective biometric control system is the one:

- A. which has the highest equal-error rate (EER).
- B. which has the lowest EER.
- C. for which the false-rejection rate (FRR) is equal to the false-acceptance rate (FAR).
- D. for which the FRR is equal to the failure-to-enroll rate (FER).

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The equal-error rate (EER) of a biometric system denotes the percent at which the false-acceptance rate (FAR) is equal to the false-rejection rate (FRR). The biometric that has the lowest EER is the most effective. The biometric that has the highest EER is the most ineffective. For any biometric, there will be a measure at which the FRR will be equal to the FAR. This is the EER. FER is an aggregate measure of FRR.

QUESTION 808

Which of the following is the BEST way to satisfy a two-factor user authentication?

- A. A smart card requiring the user's PIN
- B. User ID along with password
- C. Iris scanning plus fingerprint scanning
- D. A magnetic card requiring the user's PIN

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A smart card addresses what the user has. This is generally used in conjunction with testing what the user knows, e.g., a keyboard password or personal

identification number (PIN). An ID and password, what the user knows, is a single-factor user authentication. Choice C is not a two-factor user authentication because it is

only biometric. Choice D is similar to choice A, but the magnetic card may be copied; therefore, choice A is the best way to satisfy a two-factor user authentication.

QUESTION 809

What should an organization do before providing an external agency physical access to its information processing facilities (IPFs)?

- A. The processes of the external agency should be subjected to an IS audit by an independent agency.
- B. Employees of the external agency should be trained on the security procedures of the organization.
- C. Any access by an external agency should be limited to the demilitarized zone (DMZ).
- D. The organization should conduct a risk assessment and design and implement appropriate controls.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Physical access of information processing facilities (IPFs) by an external agency introduces additional threats into an organization. Therefore, a risk assessment should be conducted and controls designed accordingly. The processes of the external agency are not of concern here. It is the agency's interaction with the organization that needs to be protected. Auditing their processes would not be relevant in this scenario. Training the employees of the external agency may be one control procedure, but could be performed after access has been granted. Sometimes an external agency may require access to the processing facilities beyond the demilitarized zone (DMZ). For example, an agency which undertakes maintenance of servers may require access to the main server room. Restricting access within the DMZ will not serve the purpose.

QUESTION 810

An IS auditor is reviewing the physical security measures of an organization. Regarding the access card system, the IS auditor should be MOST concerned that:

- A. nonpersonalized access cards are given to the cleaning staff, who use a sign-in sheet but show no proof of identity.
- B. access cards are not labeled with the organization's name and address to facilitate easy return of a lost card.
- C. card issuance and rights administration for the cards are done by different departments, causing unnecessary lead time for new cards.
- D. the computer system used for programming the cards can only be replaced after three weeks in the event of a system failure.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Physical security is meant to control who is entering a secured area, so identification of all individuals is of utmost importance. It is not adequate to trust unknown external people by allowing them to write down their alleged name without proof, e.g., identity card, driver's license. Choice B is not a concern because if the name and address of the organization was written on the card, a malicious finder could use the card to enter the organization's premises. Separating card issuance from technical rights management is a method to ensure a proper segregation of duties so that no single person can produce a functioning card for a restricted area within the organization's premises. Choices B and C are good practices, not concerns. Choice D may be a concern, but not as important since a system failure of the card programming device would normally not mean that the readers do not function anymore. It simply means that no new cards can be issued, so this option is minor compared to the threat of improper identification.

QUESTION 811

Which of the following is the BEST way to handle obsolete magnetic tapes before disposing of them?

- A. Overwriting the tapes
- B. initializing the tape labels
- C. Degaussing the tapes
- D. Erasing the tapes

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The best way to handle obsolete magnetic tapes is to degauss them. This action leaves a very low residue of magnetic induction, essentially erasing the data from the tapes. Overwriting or erasing the tapes may cause magnetic errors but would not remove the data completely. Initializing the tape labels would not remove the data that follows the label.

QUESTION 812

Which of the following is the MOST important objective of data protection?

- A. identifying persons who need access to information
- B. Ensuring the integrity of information
- C. Denying or authorizing access to the IS system
- D. Monitoring logical accesses

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Maintaining data integrity is the most important objective of data security. This is a necessity if an organization is to continue as a viable and successful enterprise. The other choices are important techniques for achieving the objective of data integrity.

QUESTION 813

Which of the following aspects of symmetric key encryption influenced the development of asymmetric encryption?

- A. Processing power
- B. Volume of data
- C. Key distribution
- D. Complexity of the algorithm

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Symmetric key encryption requires that the keys be distributed. The larger the user group, the more challenging the key distribution. Symmetric key cryptosystems are generally less complicated and, therefore, use less processing power than asymmetric techniques, thus making it ideal for encrypting a large volume of data. The major disadvantage is the need to get the keys into the hands of those with whom you want to

exchange data, particularly in e-commerce environments, where customers are unknown, untrusted entities

QUESTION 814

A hard disk containing confidential data was damaged beyond repair. What should be done to the hard disk to prevent access to the data residing on it?

- A. Rewrite the hard disk with random Os and Is.
- B. Low-level format the hard disk.
- C. Demagnetize the hard disk.
- D. Physically destroy the hard disk.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Physically destroying the hard disk is the most economical and practical way to ensure that the data cannot be recovered. Rewriting data and low-level formatting are impractical, because the hard disk is damaged. Demagnetizing is an inefficient procedure, because it requires specialized and expensive equipment to be fully effective.

QUESTION 815

Which of the following is the MOST robust method for disposing of magnetic media that contains confidential information?

- A. Degaussing
- B. Defragmenting
- C. Erasing
- D. Destroying

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Destroying magnetic media is the only way to assure that confidential information cannot be recovered. Degaussing or demagnetizing is not sufficient to fully erase information from magnetic media. The purpose of defragmentation is to eliminate fragmentation in file systems and does not remove information. Erasing or deleting magnetic media does not remove the information; this method simply changes a file's indexing information.

QUESTION 816

Which of the following would MOST effectively control the usage of universal storage bus (USB) storage devices?

- A. Policies that require instant dismissal if such devices are found
- B. Software for tracking and managing USB storage devices
- C. Administratively disabling the USB port
- D. Searching personnel for USB storage devices at the facility's entrance

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Software for centralized tracking and monitoring would allow a USB usage policy to be applied to each user based on changing business requirements, and would provide for monitoring and reporting exceptions to management. A policy requiring dismissal may result in increased employee attrition and business requirements would not be properly addressed. Disabling ports would be complex to manage and might not allow for new business needs. Searching of personnel for USB storage devices at the entrance to a facility is not a practical solution since these devices are small and could be easily hidden.

QUESTION 817

An organization is disposing of a number of laptop computers. Which of the following data destruction methods would be the MOST effective?

- A. Run a low-level data wipe utility on all hard drives
- B. Erase all data file directories
- C. Format all hard drives
- D. Physical destruction of the hard drive

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The most effective method is physical destruction. Running a low-level data wipe utility may leave some residual data that could be recovered; erasing data directories and formatting hard drives are easily reversed, exposing all data on the drive to unauthorized individuals.

QUESTION 818

To ensure authentication, confidentiality and integrity of a message, the sender should encrypt the hash of the message with the sender's:

- A. public key and then encrypt the message with the receiver's private key.
- B. private key and then encrypt the message with the receiver's public key.
- C. public key and then encrypt the message with the receiver's public key.
- D. private key and then encrypt the message with the receiver's private key.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Obtaining the hash of the message ensures integrity; signing the hash of the message with the sender's private key ensures the authenticity of the origin, and encrypting the resulting message with the receiver's public key ensures confidentiality. The other choices are incorrect.

QUESTION 819

Which of the following would be the MOST significant audit finding when reviewing a point-of-sale (POS) system?

- A. invoices recorded on the POS system are manually entered into an accounting application
- B. An optical scanner is not used to read bar codes for the generation of sales invoices
- C. Frequent power outages occur, resulting in the manual preparation of invoices
- D. Customer credit card information is stored unencrypted on the local POS system

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is important for the IS auditor to determine if any credit card information is stored on the local point-of-sale (POS) system. Any such information, if stored, should be encrypted or protected by other means to avoid the possibility of unauthorized disclosure. Manually inputting sale invoices into the accounting application is an operational issue, if the POS system were to be interfaced with the financial accounting application, the overall efficiency could be improved. The nonavailability of optical scanners to read bar codes of the products and power outages are operational issues.

QUESTION 820

When reviewing the procedures for the disposal of computers, which of the following should be the GREATEST concern for the IS auditor?

- A. Hard disks are overwritten several times at the sector level, but are not reformatted before leaving the organization.
- B. All files and folders on hard disks are separately deleted, and the hard disks are formatted before leaving the organization.
- C. Hard disks are rendered unreadable by hole-punching through the platters at specific positions before leaving the organization.
- D. The transport of hard disks is escorted by internal security staff to a nearby metal recycling company, where the hard disks are registered and then shredded.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Deleting and formatting does not completely erase the data but only marks the sectors that contained files as being free. There are tools available over the Internet which allow one to reconstruct most of a hard disk's contents. Overwriting a hard disk at the sector level would completely erase data, directories, indices and master file tables. Reformatting is not necessary since all contents are destroyed. Overwriting several times makes useless some forensic measures which are able to reconstruct former contents of newly overwritten sectors by analyzing special magnetic features of the platter's surface. While hole-punching does not delete file contents, the hard disk cannot be used anymore, especially when head parking zones and track zero information are impacted. Reconstructing data would be extremely expensive since all analysis must be performed under a clean room atmosphere and is only possible within a short time frame or until the surface is corroded. Data reconstruction from shredded hard disks is virtually impossible, especially when the scrap is mixed with other metal parts. If the transport can be secured and the destruction be proved as described in the option, this is a valid method of disposal.

QUESTION 821

At a hospital, medical personal carry handheld computers which contain patient health data. These handheld computers are synchronized with PCs which transfer data from a hospital database. Which of the following would be of the most importance?

- A. The handheld computers are properly protected to prevent loss of data confidentiality, in case of theft or loss.
- B. The employee who deletes temporary files from the local PC, after usage, is authorized to maintain PCs.
- C. Timely synchronization is ensured by policies and procedures.
- D. The usage of the handheld computers is allowed by the hospital policy.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data confidentiality is a major requirement of privacy regulations. Choices B, C and D relate to internal security requirements, and are secondary when compared to compliance with data privacy laws.

QUESTION 822

Which of the following would BEST support 24/7 availability?

- A. Daily backup
- B. offsite storage
- C. Mirroring
- D. Periodic testing

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Mirroring of critical elements is a tool that facilitates immediate recoverability. Daily backup implies that it is reasonable for restoration to take place within a number of hours but not immediately. Offsite storage and periodic testing of systems do not of themselves support continuous availability.

QUESTION 823

The PRIMARY purpose of implementing Redundant Array of Inexpensive Disks (RAID) level 1 in a file server is to:

- A. achieve performance improvement.
- B. provide user authentication.
- C. ensure availability of data.
- D. ensure the confidentiality of data.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

RAID level 1 provides disk mirroring. Data written to one disk are also written to another disk. Users in the network access data in the first disk; if disk one fails, the second disk takes over. This redundancy ensures the availability of data. RAID level 1 does not improve performance, has no relevance to authentication and does nothing to provide for data confidentiality.

QUESTION 824

Which of the following is the MOST important criterion when selecting a location for an offsite storage facility for IS backup files? The offsite facility must be:

- A. physically separated from the data center and not subject to the same risks.
- B. given the same level of protection as that of the computer data center.
- C. outsourced to a reliable third party.
- D. equipped with surveillance capabilities.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is important that there be an offsite storage location for IS files and that it be in a location not subject to the same risks as the primary data center. The other choices are all issues that must be considered when establishing the offsite location, but they are not as critical as the location selection.

QUESTION 825

If a database is restored using before-image dumps, where should the process begin following an interruption?

- A. Before the last transaction
- B. After the last transaction
- C. As the first transaction after the latest checkpoint
- D. At the last transaction before the latest checkpoint

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If before images are used, the last transaction in the dump will not have updated the database prior to the dump being taken. The last transaction will not have updated the database and must be reprocessed. Program checkpoints are irrelevant in this situation.

QUESTION 826

In addition to the backup considerations for all systems, which of the following is an important consideration in providing backup for online systems?

- A. Maintaining system software parameters
- B. Ensuring periodic dumps of transaction logs
- C. Ensuring grandfather-father-son file backups
- D. Maintaining important data at an offsite location

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Ensuring periodic dumps of transaction logs is the only safe way of preserving timely historical data. The volume of activity usually associated with an online system makes other more traditional methods of backup impractical.

QUESTION 827

As updates to an online order entry system are processed, the updates are recorded on a transaction tape and a hard copy transaction log. At the end of the day, the order entry files are backed up on tape. During the backup procedure, a drive malfunctions and the order entry files are lost. Which of the following is necessary to restore these files?

- A. The previous day's backup file and the current transaction tape
- B. The previous day's transaction file and the current transaction tape
- C. The current transaction tape and the current hard copy transaction log
- D. The current hard copy transaction log and the previous day's transaction file

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The previous day's backup file will be the most current historical backup of activity in the system. The current day's transaction file will contain all of the day's activity. Therefore, the combination of these two files will enable full recovery up to the point of interruption.

QUESTION 828

An offsite information processing facility:

- A. should have the same amount of physical access restrictions as the primary processing site.
- B. should be easily identified from the outside so that, in the event of an emergency, it can be easily found.
- C. should be located in proximity to the originating site, so it can quickly be made operational.
- D. need not have the same level of environmental monitoring as the originating site.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An offsite information processing facility should have the same amount of physical control as the originating site. It should not be easily identified from the outside to prevent intentional sabotage. The offsite facility should not be subject to the same natural disaster that could affect the originating site and thus should not be located in proximity of the original site. The offsite facility should possess the same level of environmental monitoring and control as the originating site.

QUESTION 829

An IS auditor performing a review of the backup processing facilities should be MOST concerned that:

- A. adequate fire insurance exists.
- B. regular hardware maintenance is performed.
- C. offsite storage of transaction and master files exists.
- D. backup processing facilities are fully tested.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Adequate fire insurance and fully tested backup processing facilities are important elements for recovery, but without the offsite storage of transaction and master files, it is generally impossible to recover. Regular hardware maintenance does not relate to recovery.

QUESTION 830

Which of the following procedures would BEST determine whether adequate recovery/restart procedures exist?

- A. Reviewing program code
- B. Reviewing operations documentation
- C. Turning off the UPS, then the power
- D. Reviewing program documentation

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Operations documentation should contain recovery/restart procedures, so operations can return to normal processing in a timely manner. Turning off the uninterruptible power supply (UPS) and then turning off the power might create a situation for recovery and restart, but the negative effect on operations would prove this method to be undesirable. The review of program code and documentation generally does not provide evidence regarding recovery/restart procedures.

QUESTION 831

Which of the following findings should an IS auditor be MOST concerned about when performing an audit of backup and recovery and the offsite storage vault?

- A. There are three individuals with a key to enter the area.
- B. Paper documents are also stored in the offsite vault.
- C. Data files that are stored in the vault are synchronized.
- D. The offsite vault is located in a separate facility.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Choice A is incorrect because more than one person would typically need to have a key to the vault to ensure that individuals responsible for the offsite vault can take vacations and rotate duties. Choice B is not correct because an IS auditor would not be concerned with whether paper documents are stored in the offsite vault. In fact, paper documents, such as procedural documents and a copy of the contingency plan, would most likely be stored in the offsite vault, and the location of the vault is important, but not as important as the files being synchronized.

QUESTION 832

Online banking transactions are being posted to the database when processing suddenly comes to a halt. The integrity of the transaction processing is BEST ensured by:

- A. database integrity checks.
- B. validation checks.
- C. input controls.
- D. database commits and rollbacks.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Database commits ensure the data are saved to disk, while the transaction processing is underway or complete. Rollback ensures that the already completed processing is reversed back, and the data already processed are not saved to the disk in the event of the failure of the completion of the transaction processing. All other options do not ensure integrity while processing is underway.

QUESTION 833

To provide protection for media backup stored at an offsite location, the storage site should be:

- A. located on a different floor of the building.
- B. easily accessible by everyone.
- C. clearly labeled for emergency access.
- D. protected from unauthorized access.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The offsite storage site should always be protected against unauthorized access and have at least the same security requirements as the primary site. Choice A is incorrect because, if the backup is in the same building, it may suffer the same event and may be inaccessible. Choices B and C represent access risks.

QUESTION 834

Which of the following ensures the availability of transactions in the event of a disaster?

- A. Send tapes hourly containing transactions offsite,

- B. Send tapes daily containing transactions offsite.
- C. Capture transactions to multiple storage devices.
- D. Transmit transactions offsite in real time.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The only way to ensure availability of all transactions is to perform a real-time transmission to an offsite facility. Choices A and B are not in real time and, therefore, would not include all the transactions. Choice C does not ensure availability at an offsite location.

QUESTION 835

IS management has decided to install a level 1 Redundant Array of Inexpensive Disks (RAID) system in all servers to compensate for the elimination of offsite backups. The IS auditor should recommend:

- A. upgrading to a level 5 RAID.
- B. increasing the frequency of onsite backups.
- C. reinstating the offsite backups.
- D. establishing a cold site in a secure location.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A RAID system, at any level, will not protect against a natural disaster. The problem will not be alleviated without offsite backups, more frequent onsite backups or even setting up a cold site. Choices A, B and D do not compensate for the lack of offsite backup.

QUESTION 836

In which of the following situations is it MOST appropriate to implement data mirroring as the recovery strategy?

- A. Disaster tolerance is high.
- B. Recovery time objective is high.
- C. Recovery point objective is low.
- D. Recovery point objective is high.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A recovery point objective (RPO) indicates the latest point in time at which it is acceptable to recover the data. If the RPO is low, data mirroring should be implemented as the data recovery strategy. The recovery time objective (RTO) is an indicator of the disaster tolerance. The lower the RTO, the lower the disaster tolerance.

Therefore, choice C is the correct answer.

QUESTION 837

Network Data Management Protocol (NDMP) technology should be used for backup if:

- A. a network attached storage (NAS) appliance is required.
- B. the use of TCP/IP must be avoided.
- C. file permissions that can not be handled by legacy backup systems must be backed up.
- D. backup consistency over several related data volumes must be ensured.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

NDMP defines three kinds of services: a data service that interfaces with the primary storage to be backed up or restored, a tape service that interfaces with the secondary storage (primarily a tape device), and a translator service performing translations including multiplexing multiple data streams into one data stream and vice versa. NDMP services interact with each other. The result of this interaction is the establishment of an NDMP control session if the session is being used to achieve control for the backup or restore operation. It would result in an NDMP data session if the session is being used to transfer actual file system or volume data (including metadata). Control sessions are always TCP/IP-based, but data streams can be TCP/IP- or SAN- based. NDMP is more or less NAS-centric and defines a way to back up and restore data from a device, such as a NAS appliance, on which it is difficult to install a backup software agent, in the absence of NDMP, this data must be backed up as a shared drive on the LAN, which is accessed via network file protocols, such as Common Internet File System (CIFS) or Network File System (NFS), degrading backup performance. NDMP works on a block level for transferring payload data (file content) but metadata and traditional file system information needs to be handled by legacy backup systems that initiate NDMP data movement. NDMP does not know about nor takes care of consistency issues regarding related volumes (e.g., a volume to store database files, a volume to store application server data and a volume to store web server data). NDMP can be used to do backups in such an environment (e.g., SAP) but the logic required either must be put into a dedicated piece of software or must be scripted into the legacy backup software.

QUESTION 838

An organization currently using tape backups takes one full backup weekly and incremental backups daily. They recently augmented their tape backup procedures with a backup-to-disk solution. This is appropriate because:

- A. fast synthetic backups for offsite storage are supported.
- B. backup to disk is always significantly faster than backup to tape.
- C. tape libraries are no longer needed.
- D. data storage on disks is more reliable than on tapes.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Disk-to-disk (D2D) backup should not be seen as a direct replacement for backup to tape; rather, it should be viewed as part of a multitier backup architecture that takes advantage of the best features of both tape and disk technologies. Backups to disks are not dramatically faster than backups to tapes in a balanced

environment. Most often than not there is hardly a difference, since the limiting components are not tape or disk drives but the overall sustained bandwidth of the backup server's backplane. The advantage in terms of speed is in restoring performance, since all data are on hand and can be accessed randomly, resulting in a dramatic enhancement in throughput. This makes fast synthetic backups (making a full back up without touching the host's data only by using the existing incremental backups) efficient and easy. Although the cost of disks has been reduced, tape-based backup can offer an overall cost advantage over disk-only solutions. Even if RAID arrays are used for D2D storage, a failed drive must be swapped out and the RAID set rebuilt before another disk drive fails, thus making this kind of backup more risky and not suitable as a solution of last resort. In contrast, a single tape drive failure does not produce any data loss since the data resides on the tape media. In a multidrive library, the loss of the use of a single tape drive has no impact on the overall level of data protection. Conversely, the loss of a disk drive in an array can put all data at risk. This in itself reinforces the benefits of a disk-to-disk-to-any storage hierarchy, as data could be protected by a tertiary stage of disk storage and ultimately tape. Beyond the drive failure issue, tape has an inherent reliability advantage over any disk drive as it has no boot sector or file allocation table that can be infected or manipulated by a virus.

QUESTION 839

Which of the following should be the MOST important criterion in evaluating a backup solution for sensitive data that must be retained for a long period of time due to regulatory requirements?

- A. Full backup window
- B. Media costs
- C. Restore window
- D. Media reliability

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

To comply with regulatory requirements, the media should be reliable enough to ensure an organization's ability to recovery the data should they be required for any reason. Media price is a consideration, but should not be more important than the ability to provide the required reliability. Choices A and C are less critical than reliability.

QUESTION 840

In the event of a data center disaster, which of the following would be the MOST appropriate strategy to enable a complete recovery of a critical database?

- A. Daily data backup to tape and storage at a remote site
- B. Real-time replication to a remote site
- C. Hard disk mirroring to a local server
- D. Real-time data backup to the local storage area network (SAN)

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

With real-time replication to a remote site, data are updated simultaneously in two separate locations; therefore, a disaster in one site would not damage the information located in the remote site. This assumes that both sites were not affected by the disaster. Daily tape backup recovery could lose up to a day's work of data. Choices C and D take place in the same data center and could possibly be affected by the same disaster.

QUESTION 841

Which of the following backup techniques is the MOST appropriate when an organization requires extremely granular data restore points, as defined in the recovery point objective (RPO)?

- A. Virtual tape libraries
- B. Disk-based snapshots
- C. Continuous data backup
- D. Disk-to-tape backup

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The recovery point objective (RPO) is based on the acceptable data loss in the case of a disruption. In this scenario the organization needs a short RPO. Virtual tape libraries, disk-based snapshots and disk-to-tape backup would require time to complete the backup, while continuous data backup happens online (in real time).

QUESTION 842

What is the BEST backup strategy for a large database with data supporting online sales?

- A. Weekly full backup with daily incremental backup
- B. Daily full backup
- C. Clustered servers
- D. Mirrored hard disks

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Weekly full backup and daily incremental backup is the best backup strategy; it ensures the ability to recover the database and yet reduces the daily backup time requirements. A full backup normally requires a couple of hours, and therefore it can be impractical to conduct a full back up every day. Clustered servers provide a redundant processing capability, but are not a backup. Mirrored hard disks will not help in case of disaster.

QUESTION 843

During an audit, an IS auditor notes that an organization's business continuity plan (BCP) does not adequately address information confidentiality during a recovery process. The IS auditor should recommend that the plan

be modified to include:

- A. the level of information security required when business recovery procedures are invoked.
- B. information security roles and responsibilities in the crisis management structure.

- C. information security resource requirements.
- D. change management procedures for information security that could affect business continuity arrangements.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Business should consider whether information security levels required during recovery should be the same, lower or higher than when business is operating normally. In particular, any special rules for access to confidential data during a crisis need to be identified. The other choices do not directly address the information confidentiality issue.

QUESTION 844

Which of the following is the GREATEST risk when storage growth in a critical file server is not managed properly?

- A. Backup time would steadily increase
- B. Backup operational cost would significantly increase
- C. Storage operational cost would significantly increase
- D. Server recovery work may not meet the recovery time objective (RTO)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In case of a crash, recovering a server with an extensive amount of data could require a significant amount of time. If the recovery cannot meet the recovery time objective (RTO), there will be a discrepancy in IT strategies. It's important to ensure that server restoration can meet the RTO. Incremental backup would only take the backup of the daily differential, thus a steady increase in backup time is not always true. The backup and storage costs issues are not as significant as not meeting the RTO.

QUESTION 845

Which of the following is the MOST important consideration when defining recovery point objectives (RPOs)?

- A. Minimum operating requirements
- B. Acceptable data loss
- C. Mean time between failures
- D. Acceptable time for recovery

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Recovery time objectives (RTOs) are the acceptable time delay in availability of business operations, while recovery point objectives (RPOs) are the level of data loss/reworking an organization is willing to accept. Mean

time between failures and minimum operating requirements help in defining recovery strategies.

QUESTION 846

A structured walk-through test of a disaster recovery plan involves:

- A. representatives from each of the functional areas coming together to go over the plan.
- B. all employees who participate in the day-to-day operations coming together to practice executing the plan.
- C. moving the systems to the alternate processing site and performing processing operations.
- D. distributing copies of the plan to the various functional areas for review.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A structured walk-through test of a disaster recovery plan involves representatives from each of the functional areas coming together to review the plan to determine if the plan pertaining to their area is accurate and complete and can be implemented when required. Choice B is a simulation test to prepare and train the personnel who will be required to respond to disasters and disruptions. Choice C is a form of parallel testing to ensure that critical systems will perform satisfactorily in the alternate site. Choice D is a checklist test.

QUESTION 847

In a contract with a hot, warm or cold site, contractual provisions should cover which of the following considerations?

- A. Physical security measures
- B. Total number of subscribers
- C. Number of subscribers permitted to use a site at one time
- D. References by other users

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The contract should specify the number of subscribers permitted to use the site at any one time. Physical security measures are not a part of the contract, although they are an important consideration when choosing a third-party site. The total number of subscribers is not a consideration; what is important is whether the agreement limits the number of subscribers in a building or in a specific area. The references that other users can provide is a consideration taken before signing the contract; it is by no means part of the contractual provisions.

QUESTION 848

Which of the following is the GREATEST concern when an organization's backup facility is at a warm site?

- A. Timely availability of hardware
- B. Availability of heat, humidity and air conditioning equipment

- C. Adequacy of electrical power connections
- D. Effectiveness of the telecommunications network

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A warm site has the basic infrastructure facilities implemented, such as power, air conditioning and networking, but is normally lacking computing equipment. Therefore, the availability of hardware becomes a primary concern.

QUESTION 849

Which of the following recovery strategies is MOST appropriate for a business having multiple offices within a region and a limited recovery budget?

- A. A hot site maintained by the business
- B. A commercial cold site
- C. A reciprocal arrangement between its offices
- D. A third-party hot site

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

For a business having many offices within a region, a reciprocal arrangement among its offices would be most appropriate. Each office could be designated as a recovery site for some other office. This would be the least expensive approach to providing an acceptable level of confidence. A hot site maintained by the business would be a costly solution but would provide a high degree of confidence. Multiple cold sites leased for the multiple offices would lead to a costly solution with a high degree of confidence. A third-party facility for recovery is provided by a traditional hot site. This would be a costly approach providing a high degree of confidence.

QUESTION 850

The PRIMARY purpose of a business impact analysis (BIA) is to:

- A. provide a plan for resuming operations after a disaster.
- B. identify the events that could impact the continuity of an organization's operations.
- C. publicize the commitment of the organization to physical and logical security.
- D. provide the framework for an effective disaster recovery plan.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A business impact analysis (BIA) is one of the key steps in the development of a business continuity plan (BCP). A BIA will identify the diverse events that could impact the continuity of the operations of an organization.

QUESTION 851

After implementation of a disaster recovery plan, pre-disaster and post-disaster operational costs for an organization will:

- A. decrease.
- B. not change (remain the same).
- C. increase.
- D. increase or decrease depending upon the nature of the business.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

There are costs associated with all activities and disaster recovery planning (DRP) is not an exception. Although there are costs associated with a disaster recovery plan, there are unknown costs that are incurred if a disaster recovery plan is not implemented.

QUESTION 852

Which of the following is the MOST reasonable option for recovering a noncritical system?

- A. Warm site
- B. Mobile site
- C. Hot site
- D. Cold site

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Generally, a cold site is contracted for a longer period at a lower cost. Since it requires more time to make a cold site operational, it is generally used for noncritical applications. A warm site is generally available at a medium cost, requires less time to become operational and is suitable for sensitive operations. A mobile site is a vehicle ready with all necessary computer equipment that can be moved to any cold or warm site depending upon the need. The need for a mobile site depends upon the scale of operations. A hot site is contracted for a shorter time period at a higher cost and is better suited for recovery of vital and critical applications.

QUESTION 853

An organization's disaster recovery plan should address early recovery of:

- A. all information systems processes.
- B. all financial processing applications.
- C. only those applications designated by the IS manager.
- D. processing in priority order, as defined by business management.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Business management should know which systems are critical and when they need to process well in advance of a disaster. It is management's responsibility to develop and maintain the plan. Adequate time will not be available for this determination once the disaster occurs. IS and the information processing facility are service organizations that exist for the purpose of assisting the general user management in successfully performing their jobs.

QUESTION 854

Am advantage of the use of hot sites as a backup alternative is that:

- A. the costs associated with hot sites are low.
- B. hot sites can be used for an extended amount of time.
- C. hot sites can be made ready for operation within a short period of time.
- D. they do not require that equipment and systems software be compatible with the primary site.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Hot sites can be made ready for operation normally within hours. However, the use of hot sites is expensive, should not be considered as a long-term solution, and requires that equipment and systems software be compatible with the primary installation being backed up.

QUESTION 855

Which of the following is a practice that should be incorporated into the plan for testing disaster recovery procedures?

- A. Invite client participation.
- B. involve all technical staff.
- C. Rotate recovery managers.
- D. install locally-stored backup.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Recovery managers should be rotated to ensure the experience of the recovery plan is spread among the managers. Clients may be involved but not necessarily in every case. Not all technical staff should be involved in each test. Remote or offsite backup should always be used.

QUESTION 856

Disaster recovery planning (DRP) addresses the:

- A. technological aspect of business continuity planning.
- B. operational piece of business continuity planning.
- C. functional aspect of business continuity planning.
- D. overall coordination of business continuity planning.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Disaster recovery planning (DRP) is the technological aspect of business continuity planning. Business resumption planning addresses the operational part of business continuity planning.

QUESTION 857

An IS auditor conducting a review of disaster recovery planning (DRP) at a financial processing organization has discovered the following:

- The existing disaster recovery plan was compiled two years earlier by a systems analyst in the organization's IT department using transaction flow projections from the operations department.
- The plan was presented to the deputy CEO for approval and formal issue, but it is still awaiting their attention.
- the plan has never been updated, tested or circulated to key management and staff, though interviews show

that each would know what action to take for its area in the event of a disruptive incident.

The IS auditor's report should recommend that:

- A. the deputy CEO be censured for their failure to approve the plan.
- B. a board of senior managers is set up to review the existing plan.
- C. the existing plan is approved and circulated to all key management and staff.
- D. a manager coordinates the creation of a new or revised plan within a defined time limit.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary concern is to establish a workable disaster recovery plan, which reflects current processing volumes to protect the organization from any disruptive incident. Censuring the deputy CEO will not achieve this and is generally not within the scope of an IS auditor to recommend. Establishing a board to review the plan, which is two years out of date, may achieve an updated plan, but is not likely to be a speedy operation, and issuing the existing plan would be folly without first ensuring that it is workable. The best way to achieve a disaster recovery plan in a short time is to make an experienced manager responsible for coordinating the knowledge of other managers into a single, formal document within a defined time limit.

QUESTION 858

An IS auditor conducting a review of disaster recovery planning (DRP) at a financial processing organization has discovered the following:

- The existing disaster recovery plan was compiled two years earlier by a systems analyst in the organization's IT department using transaction flow projections from the operations department.

-The plan was presented to the deputy CEO for approval and formal issue, but it is still awaiting his/her attention.

-The plan has never been updated, tested or circulated to key management and staff, though interviews show that each would know what action to take for its area in the event of a disruptive incident.

The basis of an organization's disaster recovery plan is to reestablish live processing at an alternative site where a similar, but not identical, hardware configuration is already established. An IS auditor should:

- A. take no action as the lack of a current plan is the only significant finding.
- B. recommend that the hardware configuration at each site is identical.
- C. perform a review to verify that the second configuration can support live processing.
- D. report that the financial expenditure on the alternative site is wasted without an effective plan.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor does not have a finding unless it can be shown that the alternative hardware cannot support the live processing system. Even though the primary finding is the lack of a proven and communicated disaster recovery plan, it is essential that this aspect of recovery is included in the audit. If it is found to be inadequate, the finding will materially support the overall audit opinion. It is certainly not appropriate to take no action at all, leaving this important factor untested. Unless it is shown that the alternative site is inadequate, there can be no comment on the expenditure, even if this is considered a proper comment for the IS auditor to make. Similarly,

there is no need for the configurations to be identical. The alternative site could actually exceed the recovery requirements if it is also used for other work, such as other processing or systems development and testing. The only proper course of action at this point would be to find out if the recovery site can actually cope with a recovery.

QUESTION 859

Disaster recovery planning (DRP) for a company's computer system usually focuses on:

- A. operations turnover procedures.
- B. strategic long-range planning.
- C. the probability that a disaster will occur.
- D. alternative procedures to process transactions.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is important that disaster recovery identifies alternative processes that can be put in place while the system is not available.

QUESTION 860

The MAIN purpose for periodically testing offsite facilities is to:

- A. protect the integrity of the data in the database.
- B. eliminate the need to develop detailed contingency plans.
- C. ensure the continued compatibility of the contingency facilities.
- D. ensure that program and system documentation remains current.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The main purpose of offsite hardware testing is to ensure the continued compatibility of the contingency facilities. Specific software tools are available to protect the ongoing integrity of the database. Contingency plans should not be eliminated and program and system documentation should be reviewed continuously for currency.

QUESTION 861

A large chain of shops with electronic funds transfer (EFT) at point-of-sale devices has a central communications processor for connecting to the banking network. Which of the following is the BEST disaster recovery plan for the communications processor?

- A. Offsite storage of daily backups
- B. Alternative standby processor onsite
- C. installation of duplex communication links
- D. Alternative standby processor at another network node

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Having an alternative standby processor at another network node would be the best solution. The unavailability of the central communications processor would disrupt all access to the banking network, resulting in the disruption of operations for all of the shops. This could be caused by failure of equipment, power or communications. Offsite storage of backups would not help, since EFT tends to be an online process and offsite storage will not replace the dysfunctional processor. The provision of an alternate processor onsite would be fine if it were an equipment problem, but would not help in the case of a power outage, installation of duplex communication links would be most appropriate if it were only the communication link that failed.

QUESTION 862

Facilitating telecommunications continuity by providing redundant combinations of local carrier T-1 lines, microwaves and/or coaxial cables to access the local communication loop:

- A. last-mile circuit protection.
- B. long-haul network diversity.
- C. diverse routing.
- D. alternative routing.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The method of providing telecommunication continuity through the use of many recovery facilities, providing redundant combinations of local carrier T-Is, microwave and/or coaxial cable to access the local communication loop in the event of a disaster, is called last-mile circuit protection. Providing diverse long-distance network availability utilizing T-I circuits among major long-distance carriers is called long-haul network diversity. This ensures long-distance access should any one carrier experience a network failure. The method of routing traffic through split-cable facilities or duplicate-cable facilities is called diverse routing. Alternative routing is the method of routing information via an alternative medium, such as copper cable or fiber optics.

QUESTION 863

Which of the following represents the GREATEST risk created by a reciprocal agreement for disaster recovery made between two companies?

- A. Developments may result in hardware and software incompatibility.
- B. Resources may not be available when needed.
- C. The recovery plan cannot be tested.
- D. The security infrastructures in each company may be different.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If one organization updates its hardware and software configuration, it may mean that it is no longer compatible with the systems of the other party in the agreement. This may mean that each company is unable to use the facilities at the other company to recover their processing following a disaster. Resources being unavailable when needed are an intrinsic risk in any reciprocal agreement, but this is a contractual matter and is not the greatest risk. The plan can be tested by paper-based walkthroughs, and possibly by agreement between the companies. The difference in security infrastructures, while a risk, is not insurmountable.

QUESTION 864

Which of the following would BEST ensure continuity of a wide area network (WAN) across the organization?

- A. Built-in alternative routing
- B. Completing full system backup daily
- C. A repair contract with a service provider
- D. A duplicate machine alongside each server

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: Alternative routing would ensure the network would continue if a server is lost or if a link is severed as message rerouting could be automatic. System backup will not afford immediate protection. The repair contract is not as effective as per a nentalte (native routing). Standby servers will not provide continuity if a link is severed.

QUESTION 865

An IS auditor reviewing an organization's IS disaster recovery plan should verify that it is:

- A. tested every six months.
- B. regularly reviewed and updated.
- C. approved by the chief executive officer (CEO).
- D. communicated to every department head in the organization.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The plan should be reviewed at appropriate intervals, depending upon the nature of the business and the rate of change of systems and personnel. Otherwise, it may become out of date and may no longer be effective. The plan must be subjected to regular testing, but the period between tests will again depend on the nature of the organization and the relative importance of IS. Three months or even annually may be appropriate in different circumstances. Although the disaster recovery plan should receive the approval of senior management, it need not be the CEO if another executive officer is equally or more appropriate. For a purely IS-related plan, the executive responsible for technology may have approved the plan. Similarly, although a business continuity plan is likely to be circulated throughout an organization, the IS disaster recovery plan will usually be a technical document and only relevant to IS and communications staff.

QUESTION 866

There are several methods of providing telecommunications continuity. The method of routing traffic through split cable or duplicate cable facilities is called:

- A. alternative routing.
- B. diverse routing.
- C. long-haul network diversity.
- D. last-mile circuit protection.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Diverse routing routes traffic through split-cable facilities or duplicate-cable facilities. This can be accomplished with different and/or duplicate cable sheaths, if different cable sheaths are used, the cable may be in the same conduit and, therefore, subject to the same interruptions as the cable it is backing up. The communication service subscriber can duplicate the facilities by having alternate routes, although the entrance to and from the customer premises may be in the same conduit. The subscriber can obtain diverse routing and alternate routing from the local carrier, including dual-entrance facilities. This type of access is time consuming and costly. Alternative routing is a method of routing information via an alternate medium, such as copper cable or fiber optics. This involves use of different networks, circuits or end points should the normal network be unavailable. Long-haul network diversity is a diverse, long-distance network utilizing T-I circuits among the major long-distance carriers. It ensures long-distance access should any carrier experience a network failure. Last-mile circuit protection is a redundant combination of local carrier T-Is, microwave and/or coaxial cable access to the local communications loop. This enables the facility to have access during a local carrier communication disaster. Alternate local-carrier routing is also utilized.

QUESTION 867

The responsibilities of a disaster recovery relocation team include:

- A. obtaining, packaging and shipping media and records to the recovery facilities, as well as establishing and overseeing an offsite storage schedule.
- B. locating a recovery site, if one has not been predetermined, and coordinating the transport of company employees to the recovery site.
- C. managing the relocation project and conducting a more detailed assessment of the damage to the facilities and equipment.
- D. coordinating the process of moving from the hot site to a new location or to the restored original location.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Choice A describes an offsite storage team, choice B defines a transportation team and choice C defines a salvage team.

QUESTION 868

While reviewing the business continuity plan of an organization, an IS auditor observed that the organization's data and software files are backed up on a periodic basis. Which characteristic of an effective plan does this demonstrate?

- A. Deterrence
- B. Mitigation
- C. Recovery
- D. Response

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An effective business continuity plan includes steps to mitigate the effects of a disaster. Files must be restored on a timely basis for a backup plan to be effective. An example of deterrence is when a plan includes installation of firewalls for information systems. An example of recovery is when a plan includes an organization's hot site to restore normal business operations.

QUESTION 869

Which of the following disaster recovery/continuity plan components provides the GREATEST assurance of recovery after a disaster?

- A. The alternate facility will be available until the original information processing facility is restored.
- B. User management is involved in the identification of critical systems and their associated critical recovery times.
- C. Copies of the plan are kept at the homes of key decision-making personnel.
- D. Feedback is provided to management assuring them that the business continuity plans are indeed workable and that the procedures are current.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The alternate facility should be made available until the original site is restored to provide the greatest assurance of recovery after a disaster. Without this assurance, the plan will not be successful. All other choices ensure prioritization or the execution of the plan.

QUESTION 870

Which of the following must exist to ensure the viability of a duplicate information processing facility?

- A. The site is near the primary site to ensure quick and efficient recovery.
- B. The site contains the most advanced hardware available.
- C. The workload of the primary site is monitored to ensure adequate backup is available.
- D. The hardware is tested when it is installed to ensure it is working properly.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Resource availability must be assured. The workload of the site must be monitored to ensure that availability for emergency backup use is not impaired. The site chosen should not be subject to the same natural disaster as the primary site. In addition, a reasonable compatibility of hardware/software must exist to serve as a basis for backup. The latest or newest hardware may not adequately serve this need. Testing the hardware when the site is established is essential, but regular testing of the actual backup data is necessary to ensure the operation will continue to perform as planned.

QUESTION 871

An offsite information processing facility with electrical wiring, air conditioning and flooring, but no computer or communications equipment, is a:

- A. cold site.
- B. warm site.
- C. dial-up site.
- D. duplicate processing facility.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A cold site is ready to receive equipment but does not offer any components at the site in advance of the need. A warm site is an offsite backup facility that is partially configured with network connections and selected peripheral equipment-such as disk and tape units, controllers and CPUs-to operate an information processing facility. A duplicate information processing facility is a dedicated, self-developed recovery site that can back up critical applications.

QUESTION 872

A disaster recovery plan for an organization should:

- A. reduce the length of the recovery time and the cost of recovery.
- B. increase the length of the recovery time and the cost of recovery.

- C. reduce the duration of the recovery time and increase the cost of recovery.
- D. affect neither the recovery time nor the cost of recovery.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

One of the objectives of a disaster recovery plan is to reduce the duration and cost of recovering from a disaster. A disaster recovery plan would increase the cost of operations before and after the disaster occurs, but should reduce the time to return to normal operations and the cost that could result from a disaster.

QUESTION 873

A disaster recovery plan for an organization's financial system specifies that the recovery point objective (RPO) is no data loss and the recovery time objective (RTO) is 72 hours. Which of the following is the MOST cost-effective solution?

- A. A hot site that can be operational in eight hours with asynchronous backup of the transaction logs
- B. Distributed database systems in multiple locations updated asynchronously
- C. Synchronous updates of the data and standby active systems in a hot site
- D. Synchronous remote copy of the data in a warm site that can be operational in 48 hours

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The synchronous copy of the storage achieves the RPO objective and a warm site operational in 48 hours meets the required RTO. Asynchronous updates of the database in distributed locations do not meet the RPO. Synchronous updates of the data and standby active systems in a hot site meet the RPO and RTO requirements but are more costly than a warm site solution.

QUESTION 874

A financial institution that processes millions of transactions each day has a central communications processor (switch) for connecting to automated teller machines (ATMs). Which of the following would be the BEST contingency plan for the communications processor?

- A. Reciprocal agreement with another organization
- B. Alternate processor in the same location
- C. Alternate processor at another network node
- D. Installation of duplex communication links

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The unavailability of the central communications processor would disrupt all access to the banking network. This could be caused by an equipment, power or communications failure. Reciprocal agreements make an organization dependent on the other organization and raise privacy, competition and regulatory issues. Having an alternate processor in the same location resolves the equipment problem, but would not be effective if the failure was caused by environmental conditions (i.e., power disruption). The installation of duplex communication links would only be appropriate if the failure were limited to the communication link.

QUESTION 875

The cost of ongoing operations when a disaster recovery plan is in place, compared to not having a disaster recovery plan, will MOST likely:

- A. increase.
- B. decrease.
- C. remain the same.
- D. be unpredictable.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Due to the additional cost of disaster recovery planning (DRP) measures, the cost of normal operations for any organization will always increase after a DRP implementation, i.e., the cost of normal operations during a nondisaster period will be more than the cost of operations during a nondisaster period when no disaster recovery plan was in place.

QUESTION 876

Which of the following tasks should be performed FIRST when preparing a disaster recovery plan?

- A. Develop a recovery strategy.
- B. Perform a business impact analysis.
- C. Map software systems, hardware and network components.
- D. Appoint recovery teams with defined personnel, roles and hierarchy.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The first step in any disaster recovery plan is to perform a business impact analysis. All other tasks come afterwards.

QUESTION 877

Which of the following provides the BEST evidence of an organization's disaster recovery readiness?

- A. A disaster recovery plan
- B. Customer references for the alternate site provider
- C. Processes for maintaining the disaster recovery plan
- D. Results of tests and drills

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Plans are important, but mere plans do not provide reasonable assurance unless tested. References for the alternate site provider and the existence and maintenance of a disaster recovery plan are important, but only tests and drills demonstrate the adequacy of the plans and provide reasonable assurance of an organization's disaster recovery readiness.

QUESTION 878

Which of the following is the BEST method for determining the criticality of each application system in the production environment?

- A. interview the application programmers.
- B. Perform a gap analysis.
- C. Review the most recent application audits.
- D. Perform a business impact analysis.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A business impact analysis will give the impact of the loss of each application. Interviews with the application programmers will provide limited information related to the criticality of the systems. A gap analysis is only relevant to systems development and project management. The audits may not contain the required information or may not have been done recently.

QUESTION 879

A hot site should be implemented as a recovery strategy when the:

- A. disaster tolerance is low.
- B. recovery point objective (RPO) is high.
- C. recovery time objective (RTO) is high.
- D. disaster tolerance is high.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Disaster tolerance is the time gap during which the business can accept nonavailability of IT facilities. If this time gap is low, recovery strategies that can be implemented within a short period of time, such as a hot site, should be used. The RPO is the earliest point in time at which it is acceptable to recover the data. A high RPO means that the process can wait for a longer time. In such cases, other recovery alternatives, such as warm or cold sites, should be considered. A high RTO means that additional time would be available for the recovery strategy, thus making other recovery alternatives-such as warm or cold sites- viable alternatives.

QUESTION 880

An organization has implemented a disaster recovery plan. Which of the following steps should be carried out next?

- A. Obtain senior management sponsorship.
- B. Identify business needs.
- C. Conduct a paper test.
- D. Perform a system restore test.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A best practice would be to conduct a paper test. Senior management sponsorship and business needs identification should have been obtained prior to implementing the plan. A paper test should be conducted first, followed by system or full testing.

QUESTION 881

When auditing a disaster recovery plan for a critical business area, an IS auditor finds that it does not cover all the systems. Which of the following is the MOST appropriate action for the IS auditor?

- A. Alert management and evaluate the impact of not covering all systems.
- B. Cancel the audit.
- C. Complete the audit of the systems covered by the existing disaster recovery plan.
- D. Postpone the audit until the systems are added to the disaster recovery plan.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor should make management aware that some systems are omitted from the disaster recovery plan. An IS auditor should continue the audit and include an evaluation of the impact of not including all systems in the disaster recovery plan. Cancelling the audit, ignoring the fact that some systems are not covered or postponing the audit are inappropriate actions to take.

QUESTION 882

Which of the following should be of MOST concern to an IS auditor reviewing the BCP?

- A. The disaster levels are based on scopes of damaged functions, but not on duration.
- B. The difference between low-level disaster and software incidents is not clear.
- C. The overall BCP is documented, but detailed recovery steps are not specified.
- D. The responsibility for declaring a disaster is not identified.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If nobody declares the disaster, the response and recovery plan would not be invoked, making all other concerns mute. Although failure to consider duration could be a problem, it is not as significant as scope, and neither is as critical as the need to have someone invoke the plan. The difference between incidents and low-level disasters is always unclear and frequently revolves around the amount of time required to correct the damage. The lack of detailed steps should be documented, but their absence does not mean a lack of recovery, if in fact someone has invoked the plan.

QUESTION 883

Of the following alternatives, the FIRST approach to developing a disaster recovery strategy would be to assess whether:

- A. all threats can be completely removed.
- B. a cost-effective, built-in resilience can be implemented.
- C. the recovery time objective can be optimized.
- D. the cost of recovery can be minimized.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

It is critical to initially identify information assets that can be made more resilient to disasters, e.g., diverse routing, alternate paths or multiple communication carriers. It is impossible to remove all existing and future threats. The optimization of the recovery time objective and efforts to minimize the cost of recovery come later in the development of the disaster recovery strategy.

QUESTION 884

An organization has a number of branches across a wide geographical area. To ensure that all aspects of the disaster recovery plan are evaluated in a cost effective manner, an IS auditor should recommend the use of a:

- A. data recovery test.
- B. full operational test.
- C. posttest.
- D. preparedness test.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A preparedness test should be performed by each local office/area to test the adequacy of the preparedness of local operations in the event of a disaster. This test should be performed regularly on different aspects of the plan and can be a cost-effective way to gradually obtain evidence of the plan's adequacy. A data recovery test is a partial test and will not ensure that all aspects are evaluated. A full operational test is not the most cost effective test in light of the geographical dispersion of the branches, and a posttest is a phase of the test execution process.

QUESTION 885

If the recovery time objective (RTO) increases:

- A. the disaster tolerance increases.
- B. the cost of recovery increases.
- C. a cold site cannot be used.
- D. the data backup frequency increases.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The longer the recovery time objective (RTO), the higher disaster tolerance and the lower the recovery cost. It cannot be concluded that a cold site is inappropriate or that the frequency of data backup would increase.

QUESTION 886

Due to changes in IT, the disaster recovery plan of a large organization has been changed. What is the PRIMARY risk if the new plan is not tested?

- A. Catastrophic service interruption
- B. High consumption of resources
- C. Total cost of the recovery may not be minimized
- D. Users and recovery teams may face severe difficulties when activating the plan

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Choices B, C and D are all possible problems that might occur, and would cause difficulties and financial losses or waste of resources. However, if a new disaster recovery plan is not tested, the possibility of a catastrophic service interruption is the most critical of all risks.

QUESTION 887

When developing a disaster recovery plan, the criteria for determining the acceptable downtime should be the:

- A. annualized loss expectancy (ALE).
- B. service delivery objective.
- C. quantity of orphan data.
- D. maximum tolerable outage.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The recovery time objective is determined based on the acceptable downtime in case of a disruption of operations, it indicates the maximum tolerable outage that an organization considers to be acceptable before a system or process must resume following a disaster. Choice A is incorrect, because the acceptable downtime would not be determined by the annualized loss expectancy (ALE). Choices B and C are relevant to business continuity, but they are not determined by acceptable downtime.

QUESTION 888

A lower recovery time objective (RTO) results in:

- A. higher disaster tolerance.
- B. higher cost.
- C. wider interruption windows.
- D. more permissive data loss.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A recovery time objective (RTO) is based on the acceptable downtime in case of a disruption of operations. The lower the RTO, the higher the cost of recovery strategies. The lower the disaster tolerance, the narrower the interruption windows, and the lesser the permissive data loss.

QUESTION 889

Regarding a disaster recovery plan, the role of an IS auditor should include:

- A. identifying critical applications.
- B. determining the external service providers involved in a recovery test.
- C. observing the tests of the disaster recovery plan. determining the criteria for
- D. establishing a recovery time objective (RTO).

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The IS auditor should be present when disaster recovery plans are tested, to ensure that the test meets the targets for restoration, and the recovery procedures are effective and efficient. As appropriate, the auditor should provide a report of the test results. All other choices are a responsibility of management.

QUESTION 890

During a disaster recovery test, an IS auditor observes that the performance of the disaster recovery site's server is slow. To find the root cause of this, the IS auditor should FIRST review the:

- A. event error log generated at the disaster recovery site.
- B. disaster recovery test plan.
- C. disaster recovery plan (DRP).
- D. configurations and alignment of the primary and disaster recovery sites.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Since the configuration of the system is the most probable cause, the IS auditor should review that first. If the issue cannot be clarified, the IS auditor should then review the event error log. The disaster recovery test plan and the disaster recovery plan (DRP) would not contain information about the system configuration.

QUESTION 891

An organization has a recovery time objective (RTO) equal to zero and a recovery point objective (RPO) close to 1 minute for a critical system. This implies that the system can tolerate:

- A. a data loss of up to 1 minute, but the processing must be continuous.
- B. a 1-minute processing interruption but cannot tolerate any data loss.
- C. a processing interruption of 1 minute or more.
- D. both a data loss and processing interruption longer than 1 minute.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The recovery time objective (RTO) measures an organization's tolerance for downtime and the recovery point objective (RPO) measures how much data loss can be accepted. Choices B, C and D are incorrect since they exceed the RTO limits set by the scenario.

QUESTION 892

Which of the following issues should be the GREATEST concern to the IS auditor when reviewing an IT disaster recovery test?

- A. Due to the limited test time window, only the most essential systems were tested. The other systems were tested separately during the rest of the year.
- B. During the test it was noticed that some of the backup systems were defective or not working, causing the test of these systems to fail.
- C. The procedures to shut down and secure the original production site before starting the backup site required far more time than planned.
- D. Every year, the same employees perform the test. The recovery plan documents are not used since every step is well known by all participants.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A disaster recovery test should test the plan, processes, people and IT systems. Therefore, if the plan is not used, its accuracy and adequacy cannot be verified. Disaster recovery should not rely on key staff since a disaster can occur when they are not available. It is common that not all systems can be tested in a limited test time frame. It is important, however, that those systems which are essential to the business are tested, and that the other systems are eventually tested throughout the year. One aim of the test is to identify and replace defective devices so that all systems can be replaced in the case of a disaster. Choice B would only be a concern if the number of discovered problems is systematically very high, in a real disaster, there is no need for a clean shutdown of the original

production environment since the first priority is to bring the backup site up.

QUESTION 893

The frequent updating of which of the following is key to the continued effectiveness of a disaster recovery plan (DRP)?

- A. Contact information of key personnel
- B. Server inventory documentation
- C. individual roles and responsibilities
- D. Procedures for declaring a disaster

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In the event of a disaster, it is important to have a current updated list of personnel who are key to the operation of the plan. Choices B, C and D would be more likely to remain stable overtime.

QUESTION 894

A live test of a mutual agreement for IT system recovery has been carried out, including a four- hour test of intensive usage by the business units. The test has been successful, but gives only partial assurance that the:

- A. system and the IT operations team can sustain operations in the emergency environment.
- B. resources and the environment could sustain the transaction load.
- C. connectivity to the applications at the remote site meets response time requirements.
- D. workflow of actual business operations can use the emergency system in case of a disaster.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The applications have been intensively operated, therefore choices B, C and D have been actually tested, but the capability of the system and the IT operations team to sustain and support this environment (ancillary operations, batch closing, error corrections, output distribution, etc.) is only partially tested.

QUESTION 895

To address an organization's disaster recovery requirements, backup intervals should not exceed the:

- A. service level objective (SLO).
- B. recovery time objective (RTO).
- C. recovery point objective (RPO).
- D. maximum acceptable outage (MAO).

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The recovery point objective (RPO) defines the point in time to which data must be restored after a disaster so as to resume processing transactions. Backups should be performed in a way that the latest backup is no older than this maximum time frame. If service levels are not met, the usual consequences are penalty payments, not cessation of business. Organizations will try to set service level objectives (SLOs) so as to meet established targets. The resulting time for the service level agreement (SLA) will usually be longer than the RPO. The recovery time objective (RTO) defines the time period after the disaster in which normal business functionality needs to be restored. The maximum acceptable outage (MAO) is the maximum amount of system downtime that is tolerable. It can be used as a synonym for RTO. However, the RTO denotes an objective/ target, while the MAO constitutes a vital necessity for an organization's survival.

QUESTION 896

After completing the business impact analysis (BIA), what is the next step in the business continuity planning process?

- A. Test and maintain the plan.
- B. Develop a specific plan.
- C. Develop recovery strategies.
- D. implement the plan.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The next phase in the continuity plan development is to identify the various recovery strategies and select the most appropriate strategy for recovering from a disaster. After selecting a strategy, a specific plan can be developed, tested and implemented.

QUESTION 897

Which of the following is an appropriate test method to apply to a business continuity plan (BCP)?

- A. Pilot
- B. Paper
- C. Unit
- D. System

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A paper test is appropriate for testing a BCP. it is a walkthrough of the entire plan, or part of the plan, involving major players in the plan's execution, who reason out what may happen in a particular disaster. Choices A, C and D are not appropriate for a BCP.

QUESTION 898

An IS auditor has audited a business continuity plan (BCP). Which of the following findings is the MOST critical?

- A. Nonavailability of an alternate private branch exchange (PBX) system
- B. Absence of a backup for the network backbone
- C. Lack of backup systems for the users' PCs
- D. Failure of the access card system

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Failure of a network backbone will result in the failure of the complete network and impact the ability of all users to access information on the network. The nonavailability of an alternate PBX system will result in users not being able to make or receive telephone calls or faxes; however, users may have alternate means of communication, such as a mobile phone or e-mail. Lack of backup systems for user PCs will impact only the specific users, not all users. Failure of the access card system impacts the ability to maintain records of the users who are entering the specified work areas; however, this could be mitigated by manual monitoring controls.

QUESTION 899

As part of the business continuity planning process, which of the following should be identified FIRST in the business impact analysis?

- A. Organizational risks, such as single point-of-failure and infrastructure risk
- B. Threats to critical business processes
- C. Critical business processes for ascertaining the priority for recovery
- D. Resources required for resumption of business

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The identification of the priority for recovering critical business processes should be addressed first. Organizational risks should be identified next, followed by the identification of threats to critical business processes. Identification of resources for business resumption will occur after the tasks mentioned.

QUESTION 900

Which of the following activities should the business continuity manager perform FIRST after the replacement of hardware at the primary information processing facility?

- A. verify compatibility with the hot site.
- B. Review the implementation report.
- C. Perform a walk-through of the disaster recovery plan.
- D. Update the IS assets inventory.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS assets inventory is the basic input for the business continuity/disaster recovery plan, and the plan must be updated to reflect changes in the IS infrastructure. The other choices are procedures required to update the disaster recovery plan after having updated the required assets inventory.

QUESTION 1

Which of the following would contribute MOST to an effective business continuity plan (BCP)?

- A. Document is circulated to all interested parties
- B. Planning involves all user departments
- C. Approval by senior management
- D. Audit by an external IS auditor

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The involvement of user departments in the BCP is crucial for the identification of the business processing priorities. The BCP circulation will ensure that the BCP document is received by all users. Though essential, this does not contribute significantly to the success of the BCP. A BCP approved by senior management would not ensure the quality of the BCP, nor would an audit necessarily improve the quality of the BCP.

QUESTION 2

To develop a successful business continuity plan, end user involvement is critical during which of the following phases?

- A. Business recovery strategy
- B. Detailed plan development
- C. Business impact analysis (BIA)
- D. Testing and maintenance

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

End user involvement is critical in the BIA phase. During this phase the current operations of the business needs to be understood and the impact on the business of various disasters must be evaluated. End users are the appropriate persons to provide relevant information for these tasks, inadequate end user involvement in this stage could result in an inadequate understanding of business priorities and the plan not meeting the requirements of the organization.

QUESTION 3

Which of the following would an IS auditor consider to be the MOST important to review when conducting a business continuity audit?

- A. A hot site contracted and available as needed.
- B. A business continuity manual is available and current.
- C. insurance coverage is adequate and premiums are current.
- D. Media backups are performed on a timely basis and stored offsite.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Without data to process, all other components of the recovery effort are in vain. Even in the absence of a plan, recovery efforts of any type would not be practical without data to process.

QUESTION 4

The PRIMARY objective of business continuity and disaster recovery plans should be to:

- A. safeguard critical IS assets.
- B. provide for continuity of operations.
- C. minimize the loss to an organization.
- D. protect human life.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Since human life is invaluable, the main priority of any business continuity and disaster recovery plan should be to protect people. All other priorities are important but are secondary objectives of a business continuity and disaster recovery plan.

QUESTION 5

After a full operational contingency test, an IS auditor performs a review of the recovery steps. The auditor concludes that the time it took for the technological environment and systems to return to full-functioning exceeded the required critical recovery time. Which of the following should the auditor recommend?

- A. Perform an integral review of the recovery tasks.
- B. Broaden the processing capacity to gain recovery time.
- C. Make improvements in the facility's circulation structure.
- D. increase the amount of human resources involved in the recovery.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Performing an exhaustive review of the recovery tasks would be appropriate to identify the way these tasks were performed, identify the time allocated to each of the steps required to accomplish recovery, and determine where adjustments can be made. Choices B, C and D could be actions after the described review has been completed.

QUESTION 6

While designing the business continuity plan (BCP) for an airline reservation system, the MOST appropriate method of data transfer/backup at an offsite location would be:

- A. shadow file processing.
- B. electronic vaulting.
- C. hard-disk mirroring.
- D. hot-site provisioning.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In shadow file processing, exact duplicates of the files are maintained at the same site or at a remote site. The two files are processed concurrently. This is used for critical data files, such as airline booking systems. Electronic vaulting electronically transmits data either to direct access storage, an optical disc or another storage medium; this is a method used by banks. Hard-disk mirroring provides redundancy in case the primary hard disk fails. All transactions and operations occur on two hard disks in the same server. A hot site is an alternate site ready to take over business operations within a few hours of any business interruption and is not a method for backing up data.

QUESTION 7

Depending on the complexity of an organization's business continuity plan (BCP), the plan may be developed as a set of more than one plan to address various aspects of business continuity and disaster recovery, in such an environment, it is essential that:

- A. each plan is consistent with one another.
- B. all plans are integrated into a single plan.
- C. each plan is dependent on one another.
- D. the sequence for implementation of all plans is defined.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Depending on the complexity of an organization, there could be more than one plan to address various aspects of business continuity and disaster recovery. These do not necessarily have to be integrated into one single plan. However, each plan has to be consistent with other plans to have a viable business continuity planning strategy. It may not be possible to define a sequence in which plans have to be implemented, as it may be dependent on the nature of disaster, criticality, recovery time, etc.

QUESTION 8

During a business continuity audit, an IS auditor found that the business continuity plan (BCP) covers only critical processes. The IS auditor should::

- A. recommend that the BCP cover all business processes.
- B. assess the impact of the processes not covered.
- C. report the findings to the IT manager.
- D. redefine the critical processes.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The business impact analysis needs to be either updated or revisited to assess the risk of not covering all processes in the plan. It is possible that the cost of including all processes might exceed the value of those processes; therefore, they should not be covered. An IS auditor should substantiate this by analyzing the risk.

QUESTION 9

An IS auditor noted that an organization had adequate business continuity plans (BCPs) for each individual process, but no comprehensive BCP. Which would be the BEST course of action for the IS auditor?

- A. Recommend that an additional comprehensive BCP be developed.
- B. Determine whether the BCPs are consistent.
- C. Accept the BCPs as written.
- D. Recommend the creation of a single BCP.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Depending on the complexity of the organization, there could be more than one plan to address various aspects of business continuity and disaster recovery. These do not necessarily have to be integrated into one single plan; however, each plan should be consistent with other plans to have a viable business continuity planning strategy.

QUESTION 10

When developing a business continuity plan (BCP), which of the following tools should be used to gain an understanding of the organization's business processes?

- A. Business continuity self-audit
- B. Resource recovery analysis
- C. Risk assessment
- D. Gap analysis

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Risk assessment and business impact assessment are tools for understanding business- for- business continuity planning. Business continuity self-audit is a tool for evaluating the adequacy of the BCP, resource recovery analysis is a tool for identifying a business resumption strategy, while the role gap analysis can play in business continuity planning is to identify deficiencies in a plan. Neither of these is used for gaining an understanding of the business.

QUESTION 11

During an audit of a business continuity plan (BCP), an IS auditor found that, although all departments were housed in the same building, each department had a separate BCP. The IS auditor recommended that the BCPs be reconciled. Which of the following areas should be reconciled FIRST?

- A. Evacuation plan
- B. Recovery priorities
- C. Backup storages
- D. Call tree

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Protecting human resources during a disaster-related event should be addressed first. Having separate BCPs could result in conflicting evacuation plans, thus jeopardizing the safety of staff and clients. Choices B, C and D may be unique to each department and could be addressed separately, but still should be reviewed for possible conflicts and/or the possibility of cost reduction, but only after the issue of human safety has been analyzed.

QUESTION 12

Management considered two projections for its business continuity plan; plan A with two months to recover and plan B with eight months to recover. The recovery objectives are the same in both plans. It is reasonable to expect that plan B projected higher:

- A. downtime costs.
- B. resumption costs.
- C. recovery costs.
- D. walkthrough costs.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Since the recovery time is longer in plan B, resumption and recovery costs can be expected to be lower. Walkthrough costs are not a part of disaster recovery. Since the management considered a higher window for recovery in plan B, downtime costs included in the plan are likely to be higher.

QUESTION 13

The optimum business continuity strategy for an entity is determined by the:

- A. lowest downtime cost and highest recovery cost.
- B. lowest sum of downtime cost and recovery cost.
- C. lowest recovery cost and highest downtime cost.
- D. average of the combined downtime and recovery cost.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Both costs have to be minimized, and the strategy for which the costs are lowest is the optimum strategy. The strategy with the highest recovery cost cannot be the optimum strategy. The strategy with the highest downtime cost cannot be the optimum strategy. The average of the combined downtime and recovery cost will be higher than the lowest combined cost of downtime and recovery.

QUESTION 14

The PRIMARY objective of testing a business continuity plan is to:

- A. familiarize employees with the business continuity plan.
- B. ensure that all residual risks are addressed.
- C. exercise all possible disaster scenarios.
- D. identify limitations of the business continuity plan.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Testing the business continuity plan provides the best evidence of any limitations that may exist. Familiarizing employees with the business continuity plan is a secondary benefit of a test. It is not cost effective to address residual risks in a business continuity plan, and it is not practical to test all possible disaster scenarios.

QUESTION 15

In determining the acceptable time period for the resumption of critical business processes:

- A. only downtime costs need to be considered.
- B. recovery operations should be analyzed.
- C. both downtime costs and recovery costs need to be evaluated.
- D. indirect downtime costs should be ignored.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Both downtime costs and recovery costs need to be evaluated in determining the acceptable time period before the resumption of critical business processes. The outcome of the business impact analysis (BIA) should be a recovery strategy that represents the optimal balance. Downtime costs cannot be looked at in isolation. The quicker information assets can be restored and business processing resumed, the smaller the downtime costs. However, the expenditure needed to have the redundant capability required to recover information resources might be prohibitive for nonessential business processes. Recovery operations do not determine the acceptable time period for the resumption of critical business processes, and indirect downtime costs should be considered in addition to the direct cash outflows incurred due to business disruption. The indirect costs of a serious disruption to normal business activity, e.g., loss of customer and supplier goodwill and loss of market share, may actually be more significant than direct costs over time, thus reaching the point where business viability is threatened.

QUESTION 16

In the event of a disruption or disaster, which of the following technologies provides for continuous operations?

- A. Load balancing
- B. Fault-tolerant hardware
- C. Distributed backups
- D. High-availability computing

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Fault-tolerant hardware is the only technology that currently supports continuous, uninterrupted service. Load balancing is used to improve the performance of the server by splitting the work between several servers based on workloads. High-availability (HA) computing facilities provide a quick but not continuous recovery, while distributed backups require longer recovery times.

QUESTION 17

Which of the following would be MOST important for an IS auditor to verify when conducting a business continuity audit?

- A. Data backups are performed on a timely basis
- B. A recovery site is contracted for and available as needed
- C. Human safety procedures are in place
- D. Insurance coverage is adequate and premiums are current

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The most important element in any business continuity process is the protection of human life. This takes precedence over all other aspects of the plan.

QUESTION 18

Which of the following insurance types provide for a loss arising from fraudulent acts by employees?

- A. Business interruption
- B. Fidelity coverage
- C. Errors and omissions
- D. Extra expense

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Fidelity insurance covers the loss arising from dishonest or fraudulent acts by employees. Business interruption insurance covers the loss of profit due to the disruption in the operations of an organization. Errors and omissions insurance provides legal liability protection in the event that the professional practitioner commits an act that results in financial loss to a client. Extra expense insurance is designed to cover the extra costs of continuing operations following a disaster/disruption within an organization.

QUESTION 19

The BEST method for assessing the effectiveness of a business continuity plan is to review the:

- A. plans and compare them to appropriate standards.
- B. results from previous tests.
- C. emergency procedures and employee training.
- D. offsite storage and environmental controls.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Previous test results will provide evidence of the effectiveness of the business continuity plan. Comparisons to standards will give some assurance that the plan addresses the critical aspects of a business continuity plan but will not reveal anything about its effectiveness. Reviewing emergency procedures, offsite storage and environmental controls would provide insight into some aspects of the plan but would fall short of providing assurance of the plan's overall effectiveness.

QUESTION 20

With respect to business continuity strategies, an IS auditor interviews key stakeholders in an organization to determine whether they understand their roles and responsibilities. The IS auditor is attempting to evaluate the:

- A. clarity and simplicity of the business continuity plans.
- B. adequacy of the business continuity plans.
- C. effectiveness of the business continuity plans.
- D. ability of IS and end-user personnel to respond effectively in emergencies.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The IS auditor should interview key stakeholders to evaluate how well they understand their roles and responsibilities. When all stakeholders have a detailed understanding of their roles and responsibilities in the event of a disaster, an IS auditor can deem the business continuity plan to be clear and simple. To evaluate adequacy, the IS auditor should review the plans and compare them to appropriate standards. To evaluate effectiveness, the IS auditor should review the results from previous tests. This is the best determination for the evaluation of effectiveness. An understanding of roles and responsibilities by key stakeholders will assist in ensuring the business continuity plan is effective. To evaluate the response, the IS auditor should review results of continuity tests. This will provide the IS auditor with assurance that target and recovery times are met. Emergency procedures and employee training need to be reviewed to determine whether the organization had implemented plans to allow for the effective response.

QUESTION 21

During the design of a business continuity plan, the business impact analysis (BIA) identifies critical processes and supporting applications. This will PRIMARILY influence the:

- A. responsibility for maintaining the business continuity plan.
- B. criteria for selecting a recovery site provider.
- C. recovery strategy.
- D. responsibilities of key personnel.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The most appropriate strategy is selected based on the relative risk level and criticality identified in the business impact analysis (BIA.) The other choices are made after the selection or design of the appropriate recovery strategy.

QUESTION 22

During a review of a business continuity plan, an IS auditor noticed that the point at which a situation is declared to be a crisis has not been defined. The MAJOR risk associated with this is that:

- A. assessment of the situation may be delayed.
- B. execution of the disaster recovery plan could be impacted.
- C. notification of the teams might not occur.
- D. potential crisis recognition might be ineffective.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: Execution of the business continuity plan would be impacted if the organization does not know when to declare a crisis. Choices A, C and D are steps that must be performed to know whether to declare a crisis. Problem and severity assessment would provide information necessary in declaring a disaster. Once a potential crisis is recognized, the teams responsible for crisis management need to be notified. Delaying this step until a disaster has been declared would negate the effect of having response teams. Potential crisis recognition is the first step in responding to a disaster.

QUESTION 23

An organization has just completed their annual risk assessment. Regarding the business continuity plan, what should an IS auditor recommend as the next step for the organization?

- A. Review and evaluate the business continuity plan for adequacy
- B. Perform a full simulation of the business continuity plan
- C. Train and educate employees regarding the business continuity plan
- D. Notify critical contacts in the business continuity plan

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The business continuity plan should be reviewed every time a risk assessment is completed for the organization. Training of the employees and a simulation should be performed after the business continuity plan has been deemed adequate for the organization. There is no reason to notify the business continuity plan contacts at this time.

QUESTION 24

Integrating business continuity planning (BCP) into an IT project aids in:

- A. the retrofitting of the business continuity requirements.
- B. the development of a more comprehensive set of requirements.
- C. the development of a transaction flowchart.
- D. ensuring the application meets the user's needs.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Integrating business continuity planning (BCP) into the development process ensures complete coverage of the requirements through each phase of the project. Retrofitting of the business continuity plan's requirements occurs when BCP is not integrating into the development methodology. Transaction flowcharts aid in analyzing an application's controls. A business continuity plan will not directly address the detailed processing needs of the users.

QUESTION 25

While observing a full simulation of the business continuity plan, an IS auditor notices that the notification systems within the organizational facilities could be severely impacted by infra structural damage. The BEST recommendation the IS auditor can provide to the organization is to ensure:

- A. the salvage team is trained to use the notification system.
- B. the notification system provides for the recovery of the backup.
- C. redundancies are built into the notification system.
- D. the notification systems are stored in a vault.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If the notification system has been severely impacted by the damage, redundancy would be the best control. The salvage team would not be able to use a severely damaged notification system, even if they are trained to use it. The recovery of the backups has no bearing on the notification system and storing the notification system in a vault would be of little value if the building is damaged.

QUESTION 26

The activation of an enterprise's business continuity plan should be based on predetermined criteria that address the:

- A. duration of the outage.
- B. type of outage.
- C. probability of the outage.
- D. cause of the outage.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The initiation of a business continuity plan (action) should primarily be based on the maximum period for which a business function can be disrupted before the disruption threatens the achievement of organizational objectives.

QUESTION 27

An organization has outsourced its wide area network (WAN) to a third-party service provider. Under these circumstances, which of the following is the PRIMARY task the IS auditor should perform during an audit of business continuity (BCP) and disaster recovery planning (DRP)?

- A. Review whether the service provider's BCP process is aligned with the organization's BCP and contractual obligations.
- B. Review whether the service level agreement (SLA) contains a penalty clause in case of failure to meet the level of service in case of a disaster.
- C. Review the methodology adopted by the organization in choosing the service provider.
- D. Review the accreditation of the third-party service provider's staff.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Reviewing whether the service provider's business continuity plan (BCP) process is aligned with the organization's BCP and contractual obligations is the correct answer since an adverse effect or disruption to the business of the service provider has a direct bearing on the organization and its customers. Reviewing whether the service level agreement (SLA) contains a penalty clause in case of failure to meet the level of service in case of a disaster is not the correct answer since the presence of penalty clauses, although an essential element of a SLA, is not a primary concern. Choices C and D are possible concerns, but of lesser importance.

QUESTION 28

An IS auditor can verify that an organization's business continuity plan (BCP) is effective by reviewing the:

- A. alignment of the BCP with industry best practices.
- B. results of business continuity tests performed by IS and end-user personnel.
- C. off-site facility, its contents, security and environmental controls.
- D. annual financial cost of the BCP activities versus the expected benefit of implementation of the plan.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The effectiveness of the business continuity plan (BCP) can best be evaluated by reviewing the results from previous business continuity tests for thoroughness and accuracy in accomplishing their stated objectives. All other choices do not provide the assurance of the effectiveness of the BCP.

QUESTION 29

To optimize an organization's business contingency plan (BCP), an IS auditor should recommend conducting a business impact analysis (BIA) in order to determine:

- A. the business processes that generate the most financial value for the organization and therefore must be recovered first.
- B. the priorities and order for recovery to ensure alignment with the organization's business strategy.
- C. the business processes that must be recovered following a disaster to ensure the organization's survival.
- D. the priorities and order of recovery which will recover the greatest number of systems in the shortest time frame.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

To ensure the organization's survival following a disaster, it is important to recover the most critical business

processes first, it is a common mistake to overemphasize value (A) rather than urgency. For example, while the processing of incoming mortgage loan payments is important from a financial perspective, it could be delayed for a few days in the event of a disaster. On the other hand, wiring funds to close on a loan, while not generating direct revenue, is far more critical because of the possibility of regulatory problems, customer complaints and reputation issues. Choices B and D are not correct because neither the long-term business strategy nor the mere number of recovered systems has a direct impact at this point in time.

QUESTION 30

A financial services organization is developing and documenting business continuity measures. In which of the following cases would an IS auditor MOST likely raise an issue?

- A. The organization uses good practice guidelines instead of industry standards and relies on external advisors to ensure the adequacy of the methodology.
- B. The business continuity capabilities are planned around a carefully selected set of scenarios which describe events that might happen with a reasonable probability.
- C. The recovery time objectives (RTOs) do not take IT disaster recovery constraints into account, such as personnel or system dependencies during the recovery phase.
- D. The organization plans to rent a shared alternate site with emergency workplaces which has only enough room for half of the normal staff.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is a common mistake to use scenario planning for business continuity. The problem is that it is impossible to plan and document actions for every possible scenario. Planning for just selected scenarios denies the fact that even improbable events can cause an organization to break down. Best practice planning addresses the four possible areas of impact in a disaster: premises, people, systems, and suppliers and other dependencies. All scenarios can be reduced to these four categories and can be handled simultaneously. There are very few special scenarios which justify an additional separate analysis, it is a good idea to use best practices and external advice for such an important topic, especially since knowledge of the right level of preparedness and the judgment about adequacy of the measures taken is not available in every organization. The recovery time objectives (RTOs) are based on the essential business processes required to ensure the organization's survival, therefore it would be inappropriate for them to be based on IT capabilities. Best practice guidelines recommend having 20%-40% of normal capacity available at an emergency site; therefore, a value of 50% would not be a problem if there are no additional factors.

QUESTION 31

A medium-sized organization, whose IT disaster recovery measures have been in place and regularly tested for years, has just developed a formal business continuity plan (BCP). A basic BCP tabletop exercise has been performed successfully. Which testing should an IS auditor recommend be performed NEXT to verify the adequacy of the new BCP?

- A. Full-scale test with relocation of all departments, including IT, to the contingency site
- B. Walk-through test of a series of predefined scenarios with all critical personnel involved
- C. IT disaster recovery test with business departments involved in testing the critical applications
- D. Functional test of a scenario with limited IT involvement

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

After a tabletop exercise has been performed, the next step would be a functional test, which includes the

mobilization of staff to exercise the administrative and organizational functions of a recovery. Since the IT part of the recovery has been tested for years, it would be more efficient to verify and optimize the business continuity plan (BCP) before actually involving IT in a full-scale test. The full-scale test would be the last step of the verification process before entering into a regular annual testing schedule. A full-scale test in the situation described might fail because it would be the first time that the plan is actually exercised, and a number of resources (including IT) and time would be wasted. The walk-through test is the most basic type of testing. Its intention is to make key staff familiar with the plan and discuss critical plan elements, rather than verifying its adequacy. The recovery of applications should always be verified and approved by the business instead of being purely IT-driven. A disaster recovery test would not help in verifying the administrative and organizational parts of the BCP which are not IT-related.

QUESTION 32

Everything not explicitly permitted is forbidden has which of the following kinds of tradeoff?

- A. it improves security at a cost in functionality.
- B. it improves functionality at a cost in security.
- C. it improves security at a cost in system performance.
- D. it improves performance at a cost in functionality.
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

"Everything not explicitly permitted is forbidden (default deny) improves security at a cost in functionality. This is a good approach if you have lots of security threats. On the other hand, ""Everything not explicitly forbidden is permitted"" (default permit) allows greater functionality by sacrificing security. This is only a good approach in an environment where security threats are non-existent or negligible."

QUESTION 33

Default permit is only a good approach in an environment where:

- A. security threats are non-existent or negligible.
- B. security threats are non-negligible.
- C. security threats are serious and severe.
- D. users are trained.
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

"Everything not explicitly permitted is forbidden (default deny) improves security at a cost in functionality. This is a good approach if you have lots of security threats. On the other hand, ""Everything not explicitly forbidden is permitted"" (default permit) allows greater functionality by sacrificing security. This is only a good approach in an environment where security threats are non-existent or negligible."

QUESTION 34

Talking about the different approaches to security in computing, the principle of regarding the computer system itself as largely an untrusted system emphasizes:

- A. most privilege
- B. full privilege
- C. least privilege
- D. null privilege
- E. None of the choices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

There are two different approaches to security in computing. One focuses mainly on external threats, and generally treats the computer system itself as a trusted system. The other regards the computer system itself as largely an untrusted system, and redesigns it to make it more secure in a number of ways. This technique enforces the principle of least privilege to great extent, where an entity has only the privileges that are needed for its function.

QUESTION 35

Which of the following refers to the proving of mathematical theorems by a computer program?

- A. Analytical theorem proving
- B. Automated technology proving
- C. Automated theorem processing
- D. Automated theorem proving
- E. None of the choices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Automated theorem proving (ATP) is the proving of mathematical theorems by a computer program. Depending on the underlying logic, the problem of deciding the validity of a theorem varies from trivial to impossible. Commercial use of automated theorem proving is mostly concentrated in integrated circuit design and verification.

QUESTION 36

Which of the following BEST describes the concept of "defense in depth"?

- A. more than one subsystem needs to be compromised to compromise the security of the system and the information it holds.
- B. multiple firewalls are implemented.
- C. multiple firewalls and multiple network OS are implemented.
- D. intrusion detection and firewall filtering are required.
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

"With 0"defense in depth", more than one subsystem needs to be compromised to compromise the security of the system and the information it holds. Subsystems should default to secure settings, and wherever possible should be designed to "fail secure" rather than "fail insecure".

QUESTION 37

"Under the concept of "defense in depth", subsystems should be designed to:"

- A. "fail insecure"
- B. "fail secure"
- C. "react to attack"
- D. "react to failure"
- E. None of the choices.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

"With 0"defense in depth", more than one subsystem needs to be compromised to compromise the security of the system and the information it holds. Subsystems should default to secure settings, and wherever possible should be designed to "fail secure" rather than "fail insecure".

QUESTION 38

Security should ALWAYS be an all or nothing issue.

- A. True
- B. True for trusted systems only
- C. True for untrusted systems only
- D. False
- E. None of the choices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Security should not be an all or nothing issue. The designers and operators of systems should assume that security breaches are inevitable in the long term. Full audit trails should be kept of system activity, so that when a security breach occurs, the mechanism and extent of the breach can be determined.

QUESTION 39

The 'trusted systems' approach has been predominant in the design of:

- A. many earlier Microsoft OS products
- B. the IBM AS/400 series
- C. the SUN Solaris series
- D. most OS products in the market
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The 'trusted systems' approach has been predominant in the design of many Microsoft OS products, due to the long-standing Microsoft policy of emphasizing functionality and 'ease of use'.

QUESTION 40

Which of the following terms generally refers to small programs designed to take advantage of a software flaw that has been discovered?

- A. exploit
- B. patch
- C. quick fix
- D. service pack
- E. malware
- F. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

"The term ""exploit"" generally refers to small programs designed to take advantage of a software flaw that has been discovered, either remote or local. The code from the exploit program is frequently reused in trojan horses and computer viruses. In some cases, a vulnerability can lie in a certain programs processing of a specific file type, such as a non-executable media file."

QUESTION 41

Codes from exploit programs are frequently reused in:

- A. trojan horses only.
- B. computer viruses only.
- C. OS patchers.
- D. eavedroppers.
- E. trojan horses and computer viruses.
- F. None of the choices.

Correct Answer: E
Explanation

Explanation/Reference:

Section: Protection of Information Assets

"The term ""exploit"" generally refers to small programs designed to take advantage of a software flaw that has been discovered, either remote or local. The code from the exploit program is frequently reused in trojan horses and computer viruses. In some cases, a vulnerability can lie in a certain programs processing of a specific file type, such as a non-executable media file."

QUESTION 42

Machines that operate as a closed system can NEVER be eavesdropped.

- A. True
- B. False

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Any data that is transmitted over a network is at some risk of being eavesdropped, or even modified by a malicious person. Even machines that operate as a closed system can be eavesdropped upon via monitoring the faint electromagnetic transmissions generated by the hardware such as TEMPEST.

QUESTION 43

TEMPEST is a hardware for which of the following purposes?

- A. Eavesdropping
- B. Social engineering
- C. Virus scanning
- D. Firewalling
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Any data that is transmitted over a network is at some risk of being eavesdropped, or even modified by a malicious person. Even machines that operate as a closed system can be eavesdropped upon via monitoring the faint electromagnetic transmissions generated by the hardware such as TEMPEST.

QUESTION 44

Human error is being HEAVILY relied upon on by which of the following types of attack?

- A. Eavesdropping
- B. DoS
- C. DDoS
- D. ATP
- E. Social Engineering
- F. None of the choices.

Correct Answer: E
Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 45

A computer system is no more secure than the human systems responsible for its operation. Malicious individuals have regularly penetrated well-designed, secure computer systems by taking advantage of the carelessness of trusted individuals, or by deliberately deceiving them. zombie computers are being HEAVILY relied upon on by which of the following types of attack?

- A. Eavedropping
- B. DoS
- C. DDoS
- D. ATP
- E. Social Engineering
- F. None of the choices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: "Distributed denial of service (DDoS) attacks are common, where a large number of compromised hosts (""zombie computers"") are used to flood a target system with network requests, thus attempting to render it unusable through resource exhaustion."

QUESTION 46

Attack amplifier is often being HEAVILY relied upon on by which of the following types of attack?

- A. Packet dropping
- B. ToS
- C. DDoS
- D. ATP
- E. Wiretapping
- F. None of the choices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Distributed denial of service (DDoS) attacks are common, where a large number of compromised hosts are used to flood a target system with network requests. One technique to exhaust victim resources is through the use of an attack amplifier - where the attacker takes advantage of poorly designed protocols on 3rd party machines in order to instruct these hosts to launch the flood.

QUESTION 47

Back Orifice is an example of:

- A. a virus.
- B. a legitimate remote control software.
- C. a backdoor that takes the form of an installed program.
- D. an eavesdropper.
- E. None of the choices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

"A backdoor may take the form of an installed program (e.g., Back Orifice) or could be in the form of an existing ""legitimate"" program, or executable file. A specific form of backdoors are rootkits, which replaces system binaries and/or hooks into the function calls of the operating system to hide the presence of other programs, users, services and open ports."

QUESTION 48

Which of the following will replace system binaries and/or hook into the function calls of the operating system to hide the presence of other programs (choose the most precise answer)?

- A. rootkits
- B. virus
- C. trojan
- D. tripwire
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

"A backdoor may take the form of an installed program (e.g., Back Orifice) or could be in the form of an existing ""legitimate"" program, or executable file. A specific form of backdoors are rootkits, which replaces system binaries and/or hooks into the function calls of the operating system to hide the presence of other programs, users, services and open ports."

QUESTION 49

Which of the following types of attack makes use of common consumer devices that can be used to transfer data surreptitiously?

- A. Direct access attacks
- B. Indirect access attacks
- C. Port attack
- D. Window attack
- E. Social attack
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Direct access attacks make use of common consumer devices that can be used to transfer data surreptitiously. Someone gaining physical access to a computer

can install all manner of devices to compromise security, including operating system modifications, software worms, keyboard loggers, and covert listening devices. The attacker can also easily download large quantities of data onto backup media or portable devices.

QUESTION 50

Which of the following types of attack almost always requires physical access to the targets?

- A. Direct access attack
- B. Wireless attack
- C. Port attack
- D. Window attack
- E. System attack
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Direct access attacks make use of common consumer devices that can be used to transfer data surreptitiously. Someone gaining physical access to a computer can install all manner of devices to compromise security, including operating system modifications, software worms, keyboard loggers, and covert listening devices. The attacker can also easily download large quantities of data onto backup media or portable devices.

QUESTION 51

Which of the following methods of encryption has been proven to be almost unbreakable when correctly used?

- A. key pair
- B. Oakley
- C. certificate
- D. 3-DES
- E. one-time pad
- F. None of the choices.

Correct Answer: E

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: It's possible to protect messages in transit by means of cryptography. One method of encryption - the one-time pad --has been proven to be unbreakable when correctly used. This method uses a matching pair of key- codes, securely distributed, which are used once-and-only-once to encode and decode a single message. Note that this method is difficult to use securely, and is highly inconvenient as well.

QUESTION 52

Which of the following encryption methods uses a matching pair of key-codes, securely distributed, which are used once-and-only-once to encode and decode a single message?

- A. Blowfish
- B. Tripwire
- C. certificate
- D. DES
- E. one-time pad
- F. None of the choices.

Correct Answer: E

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It's possible to protect messages in transit by means of cryptography. One method of encryption - the one-time pad - has been proven to be unbreakable when correctly used. This method uses a matching pair of key- codes, securely distributed, which are used once-and-only-once to encode and decode a single message. Note that this method is difficult to use securely, and is highly inconvenient as well.

QUESTION 53

Why is one-time pad not always preferable for encryption:
(Choose all that apply.)

- A. it is difficult to use securely.
- B. it is highly inconvenient to use.
- C. it requires licensing fee.
- D. it requires internet connectivity.
- E. it is Microsoft only.
- F. None of the choices.

Correct Answer: AB

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It's possible to protect messages in transit by means of cryptography. One method of encryption - the one-time pad - has been proven to be unbreakable when correctly used. This method uses a matching pair of key- codes, securely distributed, which are used once-and-only-once to encode and decode a single message. Note that this method is difficult to use securely, and is highly inconvenient as well.

QUESTION 54

You may reduce a cracker's chances of success by:
(Choose all that apply.)

- A. keeping your systems up to date using a security scanner.
- B. hiring competent people responsible for security to scan and update your systems.

- C. using multiple firewalls.
- D. using multiple firewalls and IDS.
- E. None of the choices.

Correct Answer: AB
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Only a small fraction of computer program code is mathematically proven, or even goes through comprehensive information technology audits or inexpensive but extremely valuable computer security audits, so it is quite possible for a determined cracker to read, copy, alter or destroy data in well secured computers, albeit at the cost of great time and resources. You may reduce a cracker's chances by keeping your systems up to date, using a security scanner or/and hiring competent people responsible for security.

QUESTION 55

Which of the following measures can protect systems files and data, respectively?

- A. User account access controls and cryptography
- B. User account access controls and firewall
- C. User account access controls and IPS
- D. IDS and cryptography
- E. Firewall and cryptography
- F. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

User account access controls and cryptography can protect systems files and data, respectively. On the other hand, firewalls are by far the most common prevention systems from a network security perspective as they can shield access to internal network services, and block certain kinds of attacks through packet filtering.

QUESTION 56

Which of the following is by far the most common prevention system from a network security perspective?

- A. Firewall
- B. IDS
- C. IPS
- D. Hardened OS
- E. Tripwire
- F. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

User account access controls and cryptography can protect systems files and data, respectively. On the other hand, firewalls are by far the most common prevention systems from a network security perspective as they can shield access to internal network services, and block certain kinds of attacks through packet filtering.

QUESTION 57

Which of the following are designed to detect network attacks in progress and assist in post- attack forensics?

- A. Intrusion Detection Systems
- B. Audit trails
- C. System logs
- D. Tripwire
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Intrusion Detection Systems are designed to detect network attacks in progress and assist in post-attack forensics, while audit trails and logs serve a similar function for individual systems.

QUESTION 58

"Nowadays, computer security comprises mainly ""preventive"" measures."

- A. True
- B. True only for trusted networks
- C. True only for untrusted networks
- D. False
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

"Nowadays, computer security comprises mainly ""preventive"" measures, like firewalls or an Exit Procedure. A firewall can be defined as a way of filtering network data between a host or a network and another network and is normally implemented as software running on the machine or as physical integrated hardware."

QUESTION 59

The majority of software vulnerabilities result from a few known kinds of coding defects, such as (Choose five.):

- A. buffer overflows
- B. format string vulnerabilities
- C. integer overflow
- D. code injection
- E. command injection
- F. None of the choices.

Correct Answer:

Explanation

Explanation/Reference:

Correct Answer: ABCDE

Section: Protection of Information Assets

The majority of software vulnerabilities result from a few known kinds of coding defects. Common software defects include buffer overflows, format string vulnerabilities, integer overflow, and code/command injection. Some common languages such as C and C++ are vulnerable to all of these defects. Languages such as Java are immune to some of these defects but are still prone to code/ command injection and other software defects which lead to software vulnerabilities.

QUESTION 60

ALL computer programming languages are vulnerable to command injection attack.

- A. True
- B. False

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The majority of software vulnerabilities result from a few known kinds of coding defects. Common software defects include buffer overflows, format string vulnerabilities, integer overflow, and code/command injection. Some common languages such as C and C++ are vulnerable to all of these defects. Languages such as Java are immune to some of these defects but are still prone to code/ command injection and other software defects which lead to software vulnerabilities.

QUESTION 61

Which of the following refers to an anomalous condition where a process attempts to store data beyond the boundaries of a fixed length buffer?

- A. buffer overflow
- B. format string vulnerabilities
- C. integer misappropriation
- D. code injection
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A buffer overflow is an anomalous condition where a process attempts to store data beyond the boundaries of a fixed length buffer. The result is that the extra data overwrites adjacent memory locations. The overwritten data may include other buffers, variables and program flow data.

QUESTION 62

Buffer overflow aims primarily at corrupting:

- A. system processor
- B. network firewall
- C. system memory
- D. disk storage
- E. None of the choices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A buffer overflow is an anomalous condition where a process attempts to store data beyond the boundaries of a fixed length buffer. The result is that the extra data overwrites adjacent memory locations. The overwritten data may include other buffers, variables and program flow data.

QUESTION 63

Which of the following measures can effectively minimize the possibility of buffer overflows?

- A. Sufficient bounds checking
- B. Sufficient memory
- C. Sufficient processing capability
- D. Sufficient code injection
- E. None of the choices

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Buffer overflows may cause a process to crash or produce incorrect results. They can be triggered by inputs specifically designed to execute malicious code or to make the program operate in an unintended way. As such, buffer overflows cause many software vulnerabilities and form the basis of many exploits. Sufficient bounds checking by either the programmer or the compiler can prevent buffer overflows.

QUESTION 64

Which of the following types of attack makes use of unfiltered user input as the format string parameter in the print () function of the C language?

- A. buffer overflows
- B. format string vulnerabilities
- C. integer overflow
- D. code injection
- E. command injection
- F. None of the choices.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Format string attacks are a new class of vulnerabilities recently discovered. It can be used to crash a program or to execute harmful code. The problem stems from the use of unfiltered user input as the format string parameter in certain C functions that perform formatting, such as `print()`. A malicious user may use the `%s` and `%x` format tokens, among others, to print data from the stack or possibly other locations in memory. One may also write arbitrary data to arbitrary locations using the `%n` format token.

QUESTION 65

Which of the following kinds of function are particularly vulnerable to format string attacks?

- A. C functions that perform output formatting
- B. C functions that perform integer computation
- C. C functions that perform real number subtraction
- D. VB functions that perform integer conversion
- E. SQL functions that perform string conversion
- F. SQL functions that perform text conversion

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Format string attacks are a new class of vulnerabilities recently discovered. It can be used to crash a program or to execute harmful code. The problem stems from the use of unfiltered user input as the format string parameter in certain C functions that perform formatting, such as `print()`. A malicious user may use the `%s` and `%x` format tokens, among others, to print data from the stack or possibly other locations in memory. One may also write arbitrary data to arbitrary locations using the `%n` format token.

QUESTION 66

Integer overflow occurs primarily with:

- A. string formatting
- B. debug operations
- C. output formatting
- D. input verifications
- E. arithmetic operations
- F. None of the choices.

Correct Answer: E
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An integer overflow occurs when an arithmetic operation attempts to create a numeric value that is larger than can be represented within the available storage space. On some processors the result saturates - once the maximum value is reached attempts to make it larger simply return the maximum result.

QUESTION 67

Which of the following types of attack works by taking advantage of the unenforced and unchecked assumptions the system makes about its inputs?

- A. format string vulnerabilities
- B. integer overflow
- C. code injection
- D. command injection
- E. None of the choices.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Code injection is a technique to introduce code into a computer program or system by taking advantage of the unenforced and unchecked assumptions the system makes about its inputs.

QUESTION 68

An IS auditor discovers that developers have operator access to the command line of a production environment operating system. Which of the following controls would BEST mitigate the risk of undetected and unauthorized program changes to the production environment?

- A. Commands typed on the command line are logged
- B. Hash keys are calculated periodically for programs and matched against hash keys calculated for the most recent authorized versions of the programs
- C. Access to the operating system command line is granted through an access restriction tool with preapproved rights
- D. Software development tools and compilers have been removed from the production environment

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The matching of hash keys over time would allow detection of changes to files. Choice A is incorrect because having a log is not a control, reviewing the log is a

control. Choice C is incorrect because the access was already granted-it does not matter how. Choice D is wrong because files can be copied to and from the production environment.

QUESTION 69

Which of the following is MOST likely to result from a business process reengineering (BPR) project?

- A. An increased number of people using technology
- B. Significant cost savings, through a reduction in the complexity of information technology
- C. A weaker organizational structures and less accountability
- D. Increased information protection (IP) risk will increase

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A BPR project more often leads to an increased number of people using technology, and this would be a cause for concern. Incorrect answers:

B. As BPR is often technology oriented, and this technology is usually more complex and volatile than in the past, cost savings do not often materialize in this area.
D. There is no reason for IP to conflict with a BPR project, unless the project is not run properly.

QUESTION 70

Which of the following is a telecommunication device that translates data from digital form to analog form and back to digital?

- A. Multiplexer
- B. Modem
- C. Protocol converter
- D. Concentrator

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A modem is a device that translates data from digital to analog and back to digital.

QUESTION 71

What is the PRIMARY purpose of audit trails?

- A. To document auditing efforts
- B. To correct data integrity errors
- C. To establish accountability and responsibility for processed transactions
- D. To prevent unauthorized access to data

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary purpose of audit trails is to establish accountability and responsibility for processed transactions.

QUESTION 72

A primary benefit derived from an organization employing control self-assessment (CSA) techniques is that it can:

- A. Identify high-risk areas that might need a detailed review later
- B. Reduce audit costs
- C. Reduce audit time
- D. Increase audit accuracy

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A primary benefit derived from an organization employing control self-assessment (CSA) techniques is that it can identify high-risk areas that might need a detailed review later.

QUESTION 73

Which of the following would have the HIGHEST priority in a business continuity plan (BCP)?

- A. Resuming critical processes
- B. Recovering sensitive processes
- C. Restoring the site
- D. Relocating operations to an alternative site

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The resumption of critical processes has the highest priority as it enables business processes to begin immediately after the interruption and not later than the declared mean time between failure (MTBF). Recovery of sensitive processes refers to recovering the vital and sensitive processes that can be performed manually at a tolerable cost for an extended period of time and those that are not marked as high priority. Repairing and restoring the site to original status and resuming the business operations are time consuming operations and are not the highest priority. Relocating operations to an alternative site, either temporarily or permanently depending on the interruption, is a time consuming process; moreover, relocation may not be required.

QUESTION 74

Network ILD&P are typically installed:

- A. on the organization's internal network connection.

- B. on the organization's internet network connection.
- C. on each end user stations.
- D. on the firewall.
- E. None of the choices.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Information Leakage Detection and Prevention (ILD&P) is a computer security term referring to systems designed to detect and prevent the unauthorized transmission of information from the computer systems of an organization to outsiders. Network ILD&P are gateway-based systems installed on the organization's internet network connection and analyze network traffic to search for unauthorized information transmissions. Host Based ILD&P systems run on end-user workstations to monitor and control access to physical devices and access information before it has been encrypted.

QUESTION 75

Host Based ILD&P primarily addresses the issue of:

- A. information integrity
- B. information accuracy
- C. information validity
- D. information leakage
- E. None of the choices.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Information Leakage Detection and Prevention (ILD&P) is a computer security term referring to systems designed to detect and prevent the unauthorized transmission of information from the computer systems of an organization to outsiders. Network ILD&P are gateway-based systems installed on the organization's internet network connection and analyze network traffic to search for unauthorized information transmissions. Host Based ILD&P systems run on end-user workstations to monitor and control access to physical devices and access information before it has been encrypted.

QUESTION 76

Software is considered malware based on:

- A. the intent of the creator.
- B. its particular features.
- C. its location.
- D. its compatibility.
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Malware is software designed to infiltrate or damage a computer system without the owner's informed consent. Software is considered malware based on the intent of the creator rather than any particular features. It includes computer viruses, worms, trojan horses, spyware, adware, and other malicious and unwanted software.

QUESTION 77

Which of the following are valid examples of Malware:

- A. viruses
- B. worms
- C. trojan horses
- D. spyware
- E. All of the above

Correct Answer: E
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Malware is software designed to infiltrate or damage a computer system without the owner's informed consent. Software is considered malware based on the intent of the creator rather than any particular features. It includes computer viruses, worms, trojan horses, spyware, adware, and other malicious and unwanted software.

QUESTION 78

Which of the following refers to any program that invites the user to run it but conceals a harmful or malicious payload?

- A. virus
- B. worm
- C. trojan horse
- D. spyware
- E. rootkits
- F. None of the choices.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 79

A Trojan horse's payload would almost always take damaging effect immediately.

- A. True
- B. False

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Broadly speaking, a Trojan horse is any program that invites the user to run it, but conceals a harmful or malicious payload. The payload may take effect immediately and can lead to immediate yet undesirable effects, or more commonly it may install further harmful software into the user's system to serve the creator's longer-term goals.

QUESTION 80

Which of the following terms is used more generally for describing concealment routines in a malicious program?

- A. virus
- B. worm
- C. trojan horse
- D. spyware
- E. rootkits
- F. backdoor
- G. None of the choices.

Correct Answer: E
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Rootkits can prevent a malicious process from being reported in the process table, or keep its files from being

read. Originally, a rootkit was a set of tools installed by a human attacker on a Unix system where the attacker had gained administrator access. Today, the term is used more generally for concealment routines in a malicious program.

QUESTION 81

Which of the following refers to a method of bypassing normal system authentication procedures?

- A. virus
- B. worm
- C. trojan horse
- D. spyware
- E. rootkits
- F. backdoor
- G. None of the choices.

Correct Answer: F
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A backdoor is a method of bypassing normal authentication procedures. Many computer manufacturers used to preinstall backdoors on their systems to provide technical support for customers. Hackers typically use backdoors to secure remote access to a computer, while attempting to remain hidden from casual inspection. To install backdoors, hackers prefer to use either Trojan horse or computer worm.

QUESTION 82

To install backdoors, hackers generally prefer to use:

- A. either Trojan horse or computer worm.
- B. either Tripwire or computer virus.
- C. either eavedropper or computer worm.
- D. either Trojan horse or eavedropper.
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A backdoor is a method of bypassing normal authentication procedures. Many computer manufacturers used to preinstall backdoors on their systems to provide technical support for customers. Hackers typically use backdoors to secure remote access to a computer, while attempting to remain hidden from casual inspection. To install backdoors, hackers prefer to use either Trojan horse or computer worm.

QUESTION 83

In order to coordinate the activity of many infected computers, attackers have used coordinating systems known as:

- A. wormnets
- B. trojannets
- C. spynets
- D. botnets
- E. rootnets
- F. backdoor

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

In order to coordinate the activity of many infected computers, attackers are used coordinating systems known as botnets. In a botnet, the malware or mailbot logs in to an Internet Relay Chat channel or other chat system. The attacker can then give instructions to all the infected systems simultaneously.

QUESTION 84

In a botnet, mailbot logs into a particular type of system for making coordinated attack attempts. What type of system is this?

- A. Chat system
- B. SMS system
- C. Email system
- D. Log system
- E. Kernel system
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In order to coordinate the activity of many infected computers, attackers have used coordinating systems known as botnets. In a botnet, the malware or mailbot logs in to an Internet Relay Chat channel or other chat system. The attacker can then give instructions to all the infected systems simultaneously.

QUESTION 85

Which of the following software tools is often used for stealing money from infected PC owner through taking control of the modem?

- A. System patcher
- B. Porn dialer
- C. War dialer
- D. T1 dialer
- E. T3 dialer
- F. None of the choices.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

One way of stealing money from infected PC owner is to take control of the modem and dial an expensive toll call. Dialer such as porn dialer software dials up a premium-rate telephone number and leave the line open,

charging the toll to the infected user.

QUESTION 86

Which of the following is an oft-cited cause of vulnerability of networks?

- A. software monoculture
- B. software diversification
- C. single line of defense
- D. multiple DMZ
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An oft-cited cause of vulnerability of networks is homogeneity or software monoculture. In particular, Microsoft Windows has such a large share of the market that concentrating on it will enable a cracker to subvert a large number of systems. Introducing inhomogeneity purely for the sake of robustness would however bring high costs in terms of training and maintenance.

QUESTION 87

Introducing inhomogeneity to your network for the sake of robustness would have which of the following drawbacks?

- A. poorer performance.
- B. poor scalability.
- C. weak infrastructure.
- D. high costs in terms of training and maintenance.
- E. None of the choices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An oft-cited cause of vulnerability of networks is homogeneity or software monoculture. In particular, Microsoft Windows has such a large share of the market that concentrating on it will enable a cracker to subvert a large number of systems. Introducing inhomogeneity purely for the sake of robustness would however bring high costs in terms of training and maintenance.

QUESTION 88

Which of the following may be deployed in a network as lower cost surveillance and early-warning tools?

- A. Honeypots
- B. Hardware IPSs
- C. Hardware IDSs
- D. Botnets
- E. Stateful inspection firewalls
- F. Stateful logging facilities
- G. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Honeypots, essentially decoy network-accessible resources, could be deployed in a network as surveillance and early-warning tools. Techniques used by the attackers that attempt to compromise these decoy resources are studied during and after an attack to keep an eye on new exploitation techniques.

QUESTION 89

Relatively speaking, firewalls operated at the application level of the seven layer OSI model are:

- A. almost always less efficient.
- B. almost always less effective.
- C. almost always less secure.
- D. almost always less costly to setup.
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Early attempts at producing firewalls operated at the application level of the seven-layer OSI model but this required too much CPU processing power.

Packet filters operate at the network layer and function more efficiently because they only look at the header part of a packet.

QUESTION 90

Relatively speaking, firewalls operated at the physical level of the seven-layer OSI model are:

- A. almost always less efficient.
- B. almost always less effective.
- C. almost always less secure.
- D. almost always less costly to setup.
- E. None of the choices.

Correct Answer: E

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Early attempts at producing firewalls operated at the application level of the seven-layer OSI model but this required too much CPU processing power.

Packet filters operate at the network layer and function more efficiently because they only look at the header part of a packet. NO FIREWALL operates at the physical level.

QUESTION 91

Which of the following refers to the act of creating and using an invented scenario to persuade a target to perform an action?

- A. Pretexting
- B. Backgrounding
- C. Check making
- D. Bounce checking
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Pretexting is the act of creating and using an invented scenario to persuade a target to release information or perform an action and is usually done over the telephone. It is more than a simple lie as it most often involves some prior research or set up and the use of pieces of known information.

QUESTION 92

Pretexting is an act of:

- A. DoS
- B. social engineering
- C. eavesdropping
- D. soft coding
- E. hard coding
- F. None of the choices.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Pretexting is the act of creating and using an invented scenario to persuade a target to release information or perform an action and is usually done over the telephone. It is more than a simple lie as it most often involves some prior research or set up and the use of pieces of known information.

QUESTION 93

With Deep packet inspection, which of the following OSI layers are involved?

- A. Layer 2 through Layer 7
- B. Layer 3 through Layer 7
- C. Layer 2 through Layer 6
- D. Layer 3 through Layer 6
- E. Layer 2 through Layer 5

F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Deep packet inspection (DPI) is a form of computer network packet filtering that examines the data part of a through-passing packet, searching for non- protocol compliance or predefined criteria to decide if the packet can pass.

DPI devices have the ability to look at Layer 2 through Layer 7 of the OSI model.

QUESTION 94

Squid is an example of:

- A. IDS
- B. caching proxy
- C. security proxy
- D. connection proxy
- E. dialer
- F. None of the choices.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Squid is an example of a caching proxy, not a security proxy. It has the main purpose of locally storing copies of web pages that are popular, with the benefit of saving bandwidth.

QUESTION 95

Which of the following types of firewall treats each network frame or packet in isolation?

- A. statefull firewall
- B. hardware firewall
- C. combination firewall
- D. packet filtering firewall
- E. stateless firewall
- F. None of the choices.

Correct Answer: E

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A stateless firewall treats each network frame or packet in isolation. Such a firewall has no way of knowing if any given packet is part of an existing connection, is trying to establish a new connection, or is just a rogue packet.

QUESTION 96

Which of the following types of attack involves a program that creates an infinite loop, makes lots of copies of itself, and continues to open lots of files?

- A. Local DoS attacks
- B. Remote DoS attacks
- C. Distributed DoS attacks
- D. Local Virus attacks
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Local DoS attacks can be a program that creates an infinite loop, makes lots of copies of itself, and continues to open lots of files. The best defense is to find this program and kill it.

QUESTION 97

What is the best defense against Local DoS attacks?

- A. patch your systems.
- B. run a virus checker.
- C. run an anti-spy software.
- D. find this program and kill it.
- E. None of the choices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Local DoS attacks can be a program that creates an infinite loop, makes lots of copies of itself, and continues to open lots of files. The best defense is to find this program and kill it.

QUESTION 98

Which of the following are examples of tools for launching Distributed DoS Attack (Choose four.):

- A. TFN
- B. TFN2K
- C. Trin00

- D. Stacheldrucht
- E. Tripwire

Correct Answer: ABCD

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Distributed DoS Attack is a network-based attack from many servers used remotely to send packets. Examples of tools for conducting such attack include TFN, TFN2K, Trin00, Stacheldrucht, and variants. The best defense is to make sure all systems patches are up-to-date. Also make sure your firewalls are configured appropriately.

QUESTION 99

What is the best defense against Distributed DoS Attack?

- A. patch your systems.
- B. run a virus checker.
- C. run an anti-spy software.
- D. find the DoS program and kill it.
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Distributed DoS Attack is a network-based attack from many servers used remotely to send packets. Examples of tools for conducting such attack include TFN, TFN2K, Trin00, Stacheldrucht, and variants. The best defense is to make sure all systems patches are up-to-date. Also make sure your firewalls are configured appropriately.

QUESTION 100

What is wrong with a Black Box type of intrusion detection system?

- A. you cannot patch it
- B. you cannot test it
- C. you cannot examine its internal workings from outside.
- D. you cannot tune it
- E. None of the choices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

"An intrusion detection system should be able to run continually without human supervision. The system must be reliable enough to allow it to run in the background of the system being observed. However, it should not be a "black box", because you want to ensure its internal workings are examinable from outside."

QUESTION 101

Which of the following are often considered as the first defensive line in protecting a typical data and information environment?

- A. certificates
- B. security token
- C. password
- D. biometrics
- E. None of the choices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Passwords are the first defensive line in protecting your data and information. Your users need to be made aware of what a password provides them and what can be done with their password. They also need to be made aware of the things that make up a good password versus a bad password.

QUESTION 102

Which of the following are the characteristics of a good password?

- A. It has mixed-case alphabetic characters, numbers, and symbols.
- B. It has mixed-case alphabetic characters and numbers.
- C. It has mixed-case alphabetic characters and symbols.
- D. It has mixed-case alphabetic characters, numbers, and binary codes.
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Passwords are the first defensive line in protecting your data and information. Your users need to be made aware of what a password provides them and what can be done with their password. They also need to be made aware of the things that make up a good password versus a bad password. A good password has mixed-case alphabetic characters, numbers, and symbols. Do use a password that is at least eight or more characters.

QUESTION 103

What is the recommended minimum length of a good password?

- A. 6 characters
- B. 8 characters

- C. 12 characters
- D. 18 characters
- E. 22 characters
- F. None of the choices.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Passwords are the first defensive line in protecting your data and information. Your users need to be made aware of what a password provides them and what can be done with their password. They also need to be made aware of the things that make up a good password versus a bad password. A good password has mixed-case alphabetic characters, numbers, and symbols. Do use a password that is at least eight or more characters.

QUESTION 104

Which of the following is a good tool to use to help enforcing the deployment of good passwords?

- A. password cracker
- B. local DoS attacker
- C. network hacker
- D. remote windowing tool
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

"Passwords are the first defensive line in protecting your data and information. Your users need to be made aware of what a password provides them and what can be done with their password. They also need to be made aware of the things that make up a good password versus a bad password. A good password has mixed-case alphabetic characters, numbers, and symbols. Do use a password that is at least eight or more characters. You may want to run a "password cracker" program periodically, and require users to immediately change any easily cracked passwords. In any case ask them to change their passwords every 90 to 120 days."

QUESTION 105

Which of the following is a good time frame for making changes to passwords?

- A. every 180 to 365 days
- B. every 30 to 45 days
- C. every 10 to 20 days
- D. every 90 to 120 days
- E. None of the choices.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

"Passwords are the first defensive line in protecting your data and information. Your users need to be made aware of what a password provides them and what can be done with their password. They also need to be made aware of the things that make up a good password versus a bad password. A good password has mixed-case alphabetic characters, numbers, and symbols. Do use a password that is at least eight or more characters. You may want to run a "password cracker" program periodically, and require users to immediately change any easily cracked passwords. In any case ask them to change their passwords every 90 to 120 days."

QUESTION 106

You should keep all computer rooms at reasonable temperatures, which is in between:
(Choose all that apply.)

- A. 60 - 75 degrees Fahrenheit
- B. 10 - 25 degrees Celsius
- C. 30 - 45 degrees Fahrenheit
- D. 1 - 15 degrees Celsius
- E. 20 - 35 degrees Fahrenheit
- F. 0 - 5 degrees Celsius

Correct Answer: AB
Explanation

Explanation/Reference:

Section: Protection of Information Assets

You should keep all computer rooms at reasonable temperatures, which is in between 60 - 75 degrees Fahrenheit or 10 - 25 degrees Celsius. You should also keep humidity levels at 20 - 70 percent.

QUESTION 107

You should keep all computer rooms at reasonable humidity levels, which are in between:

- A. 20 - 70 percent.
- B. 10 - 70 percent.
- C. 10 - 60 percent.
- D. 70 - 90 percent.
- E. 60 - 80 percent.
- F. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

You should keep all computer rooms at reasonable temperatures, which is in between 60 - 75 degrees Fahrenheit or 10 - 25 degrees Celsius. You should also keep humidity levels at 20 - 70 percent.

QUESTION 108

A virus typically consists of what major parts (Choose three.):

- A. a mechanism that allows them to infect other files and reproduce" a trigger that activates delivery of a "payload""
- B. a payload
- C. a signature
- D. None of the choices.

Correct Answer: ABC

Explanation

Explanation/Reference:

Section: Protection of Information Assets

"A virus typically consist of three parts, which are a mechanism that allows them to infect other files and reproduce a trigger that activates delivery of a "payload" and the payload from which the virus often gets its name. The payload is what the virus does to the victim file."

QUESTION 109

Within a virus, which component is responsible for what the virus does to the victim file?

- A. the payload
- B. the signature
- C. the trigger
- D. the premium
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

"A virus typically consist of three parts, which are a mechanism that allows them to infect other files and reproduce a trigger that activates delivery of a "payload" and the payload from which the virus often gets its name. The payload is what the virus does to the victim file."

QUESTION 110

Which of the following can be thought of as the simplest and almost cheapest type of firewall?

- A. stateful firewall
- B. hardware firewall
- C. PIX firewall
- D. packet filter
- E. None of the choices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The simplest and almost cheapest type of firewall is a packet filter that stops messages with inappropriate network addresses. It usually consists of a screening router and a set of rules that accept or reject a message based on information in the message header.

QUESTION 111

Screening router inspects traffic through examining:

- A. message header.
- B. virus payload
- C. message content
- D. attachment type
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The simplest and almost cheapest type of firewall is a packet filter that stops messages with inappropriate network addresses. It usually consists of a screening router and a set of rules that accept or reject a message based on information in the message header.

QUESTION 112

A major portion of what is required to address nonrepudiation is accomplished through the use of:

- A. strong methods for authentication and ensuring data validity
- B. strong methods for authentication and ensuring data integrity.
- C. strong methods for authorization and ensuring data integrity.
- D. strong methods for authentication and ensuring data reliability.
- E. None of the choices.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A major portion of what is required to address nonrepudiation is accomplished through the use of strong methods for authentication and ensuring data integrity.

QUESTION 113

Why is it not preferable for a firewall to treat each network frame or packet in isolation?

- A. Such a firewall has no way of knowing if any given packet is part of an existing connection, is trying to establish a new connection, or is just a rogue packet.
- B. Such a firewall is costly to setup.
- C. Such a firewall is too complicated to maintain.
- D. Such a firewall is CPU hungry.
- E. Such a firewall offers poor compatibility.
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A stateless firewall treats each network frame or packet in isolation. Such a firewall has no way of knowing if any given packet is part of an existing connection, is trying to establish a new connection, or is just a rogue packet.

QUESTION 114

Phishing attack works primarily through:

- A. email and hyperlinks
- B. SMS
- C. chat
- D. email attachment
- E. news
- F. file download
- G. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

"Phishing applies to email appearing to come from a legitimate business, requesting "verification"" of information and warning of some dire consequence if it is not done. The letter usually contains a link to a fraudulent web page that looks legitimate and has a form requesting everything from a home address to an ATM card's PIN."

QUESTION 115

Which of the following types of attack often take advantage of curiosity or greed to deliver malware?

- A. Gimmies
- B. Tripwire
- C. Icing
- D. Soft coding
- E. Pretexting
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Gimmies take advantage of curiosity or greed to deliver malware. Also known as a Trojan Horse, gimmies can arrive as an email attachment promising anything. The recipient is expected to give in to the need to the program and open the attachment. In addition, many users will blindly click on any attachments they receive that seem even mildly legitimate.

QUESTION 116

Gimmies often work through:

- A. SMS
- B. IRC chat
- C. email attachment
- D. news
- E. file download
- F. None of the choices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Gimmies take advantage of curiosity or greed to deliver malware. Also known as a Trojan Horse, gimmies can arrive as an email attachment promising anything. The recipient is expected to give in to the need to the program and open the attachment. In addition, many users will blindly click on any attachments they receive that seem even mildly legitimate.

QUESTION 117

Talking about biometric authentication, physical characteristics typically include (Choose five.):

- A. fingerprints
- B. eye retinas
- C. irises
- D. facial patterns
- E. hand measurements
- F. None of the choices.

Correct Answer:

Explanation

Explanation/Reference:

Correct Answer: ABCDE

Section: Protection of Information Assets

Biometric authentication refers to technologies that measure and analyze human physical and behavioral characteristics for authentication purposes. Physical characteristics include fingerprints, eye retinas and irises, facial patterns and hand measurements, while behavioral characteristics include signature, gait and typing patterns. Voice is often considered as a mix of both physical and behavioral characteristics.

QUESTION 118

Talking about biometric authentication, which of the following is often considered as a mix of both physical and behavioral characteristics?

- A. Voice
- B. Finger measurement
- C. Body measurement
- D. Signature
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Biometric authentication refers to technologies that measure and analyze human physical and behavioral characteristics for authentication purposes. Physical characteristics include fingerprints, eye retinas and irises, facial patterns and hand measurements, while behavioral characteristics include signature, gait and typing patterns. Voice is often considered as a mix of both physical and behavioral characteristics.

QUESTION 119

Performance of a biometric measure is usually referred to in terms of (Choose three.):

- A. failure to reject rate
- B. false accept rate
- C. false reject rate
- D. failure to enroll rate
- E. None of the choices.

Correct Answer: BCD

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Performance of a biometric measure is usually referred to in terms of the false accept rate (FAR), the false non match or reject rate (FRR), and the failure to enroll rate (FTE or FER). The FAR measures the percent of invalid users who are incorrectly accepted in, while the FRR measures the percent of valid users who are wrongly rejected.

QUESTION 120

Talking about biometric measurement, which of the following measures the percent of invalid users who are incorrectly accepted in?

- A. failure to reject rate
- B. false accept rate
- C. false reject rate
- D. failure to enroll rate
- E. None of the choices.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Performance of a biometric measure is usually referred to in terms of the false accept rate (FAR), the false non match or reject rate (FRR), and the failure to enroll rate (FTE or FER). The FAR measures the percent of invalid users who are incorrectly accepted in, while the FRR measures the percent of valid users who are wrongly rejected.

QUESTION 121

An accurate biometric system usually exhibits (Choose two.):

- A. low EER
- B. low CER
- C. high EER
- D. high CER
- E. None of the choices.

Correct Answer: AB

Explanation

Explanation/Reference:

Section: Protection of Information Assets

One most commonly used measure of real-world biometric systems is the rate at which both accept and reject errors are equal: the equal error rate (EER), also known as the cross-over error rate (CER). The lower the EER or CER, the more accurate the system is considered to be.

QUESTION 122

As part of the IEEE 802.11 standard ratified in September 1999, WEP uses which stream cipher for confidentiality?

- A. CRC-32
- B. CRC-64
- C. DES
- D. 3DES
- E. RC4

- F. RC5
- G. None of the choices.

Correct Answer: E
Explanation

Explanation/Reference:

Section: Protection of Information Assets

As part of the IEEE 802.11 standard ratified in September 1999, WEP uses the stream cipher RC4 for confidentiality and the CRC-32 checksum for integrity.

QUESTION 123

As part of the IEEE 802.11 standard ratified in September 1999, WEP uses the CRC- 32 checksum for:

- A. integrity.
- B. validity.
- C. accuracy.
- D. confidentiality.
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

As part of the IEEE 802.11 standard ratified in September 1999, WEP uses the stream cipher RC4 for confidentiality and the CRC-32 checksum for integrity.

Many WEP systems require a key in hexadecimal format. If one chooses keys that spell words in the limited 0- 9, A-F hex character set, these keys can be easily guessed.

QUESTION 124

Many WEP systems require a key in a relatively insecure format. What format is this?

- A. binary format.
- B. hexadecimal format.
- C. 128 bit format.
- D. 256 bit format.
- E. None of the choices.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

As part of the IEEE 802.11 standard ratified in September 1999, WEP uses the stream cipher RC4 for confidentiality and the CRC-32 checksum for integrity.

Many WEP systems require a key in hexadecimal format. If one chooses keys that spell words in the limited 0- 9, A-F hex character set, these keys can be easily guessed.

QUESTION 125

Wi-Fi Protected Access implements the majority of which IEEE standard?

- A. 802.11i
- B. 802.11g
- C. 802.11x
- D. 802.11v
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Wi-Fi Protected Access (WPA / WPA2) is a class of systems to secure wireless computer networks. It implements the majority of the IEEE 802.11i standard, and is designed to work with all wireless network interface cards (but not necessarily with first generation wireless access points). One major improvement in WPA over WEP is the Temporal Key Integrity Protocol (TKIP), which dynamically changes keys as the system is used.

QUESTION 126

One major improvement in WPA over WEP is the use of a protocol which dynamically changes keys as the system is used. What protocol is this?

- A. SKIP
- B. RKIP
- C. OKIP
- D. EKIP
- E. TKIP
- F. None of the choices.

Correct Answer: E
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Wi-Fi Protected Access (WPA / WPA2) is a class of systems to secure wireless computer networks. It implements the majority of the IEEE 802.11i standard, and is designed to work with all wireless network interface cards (but not necessarily with first generation wireless access points). One major improvement in WPA over WEP is the Temporal Key Integrity Protocol (TKIP), which dynamically changes keys as the system is used.

QUESTION 127

Which of the following refers to a symmetric key cipher which operates on fixedlength groups of bits with an unvarying transformation?

- A. stream cipher
- B. block cipher

- C. check cipher
- D. string cipher
- E. None of the choices.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

In cryptography, a block cipher is a symmetric key cipher which operates on fixed-length groups of bits, termed blocks, with an unvarying transformation. A stream cipher, on the other hand, operates on individual digits one at a time.

QUESTION 128

Which of the following typically consists of a computer, some real looking data and/or a network site that appears to be part of a production network but which is in fact isolated and well prepared?

- A. honeypot
- B. superpot
- C. IDS
- D. IPS
- E. firewall
- F. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

You may use a honeypot to detect and deflect unauthorized use of your information systems. A typical honeypot consists of a computer, some real looking data and/or a network site that appears to be part of a production network but which is in fact isolated and well prepared for trapping hackers.

QUESTION 129

Which of the following is a tool you can use to simulate a big network structure on a single computer?

- A. honeymoon
- B. honeytrap
- C. honeytube
- D. honeyd
- E. None of the choices.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

honeyd is a GPL licensed software you can use to simulate a big network structure on a single computer.

QUESTION 130

Which of the following are valid choices for the Apache/SSL combination (Choose three.):

- A. the Apache-SSL project
- B. third-party SSL patches
- C. the mod_ssl module
- D. the mod_css module
- E. None of the choices.

Correct Answer: ABC
Explanation

Explanation/Reference:

Section: Protection of Information Assets

On Linux you have Apache which is supposed to be a safer choice of web service. In fact you have several choices for the Apache/SSL combination, such as the Apache-SSL project (www.apache-ssl.org) using third- party SSL patches, or have Apache compiled with the mod_ssl module.

QUESTION 131

What would be the major purpose of rootkit?

- A. to hide evidence from system administrators.
- B. to encrypt files for system administrators.
- C. to corrupt files for system administrators.
- D. to hijack system sessions.
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

rootkit originally describes those recompiled Unix tools that would hide any trace of the intruder. You can say that the only purpose of rootkit is to hide evidence from system administrators so there is no way to detect malicious special privilege access attempts.

QUESTION 132

Most trojan horse programs are spread through:

- A. e-mails.
- B. MP3.
- C. MS Office.

- D. Word template.
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

"Most trojan horse programs are spread through e-mails. Some earlier trojan horse programs were bundled in "Root Kits". For example, the Linux Root Kit version 3 (lrk3) which was released in December 96 had tcp wrapper trojans included and enhanced in the kit. Portable devices that run Linux can also be affected by trojan horse. The Trojan.Linux.JBellz Trojan horse runs as a malformed .mp3 file."

QUESTION 133

The Trojan.Linux.JBellz Trojan horse runs as a malformed file of what format?

- A. e-mails.
- B. MP3.
- C. MS Office.
- D. Word template.
- E. None of the choices.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

"Most trojan horse programs are spread through e-mails. Some earlier trojan horse programs were bundled in "Root Kits". For example, the Linux Root Kit version 3 (lrk3) which was released in December 96 had tcp wrapper trojans included and enhanced in the kit. Portable devices that run Linux can also be affected by trojan horse. The Trojan.Linux.JBellz Trojan horse runs as a malformed .mp3 file."

QUESTION 134

Which of the following types of spyware was originally designed for determining the sources of error or for measuring staff productivity?

- A. Keywords logging
- B. Keystroke logging
- C. Directory logging
- D. Password logging
- E. None of the choices.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Keystroke logging (in the form of spyware) was originally a function of diagnostic tool deployed by software developers for capturing user's keystrokes. This is done for determining the sources of error or for measuring staff productivity.

QUESTION 135

You should know the difference between an exploit and a vulnerability. Which of the following refers to a weakness in the system?

- A. exploit
- B. vulnerability
- C. both

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

You should know the difference between an exploit and a vulnerability. An exploit refers to software, data, or commands capable of taking advantage of a bug, glitch or vulnerability in order to cause unintended behavior. Vulnerability in this sense refers to a weakness in the system.

QUESTION 136

Which of the following is a rewrite of ipfwadm?

- A. ipchains
- B. iptables
- C. Netfilter
- D. ipcook
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

ipchains is a free software based firewall running on earlier Linux. It is a rewrite of ipfwadm but is superseded by iptables in Linux 2.4 and above. Iptables controls the packet filtering and NAT components within the Linux kernel. It is based on Netfilter, a framework which provides a set of hooks within the Linux kernel for intercepting and manipulating network packets.

QUESTION 137

Iptables is based on which of the following frameworks?

- A. Netfilter
- B. NetDoom
- C. NetCheck
- D. NetSecure
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

ipchains is a free software based firewall running on earlier Linux. It is a rewrite of ipfwadm but is superseded by iptables in Linux 2.4 and above.

Iptables controls the packet filtering and NAT components within the Linux kernel. It is based on Netfilter, a framework which provides a set of hooks within the Linux kernel for intercepting and manipulating network

packets.

QUESTION 138

Cisco IOS based routers perform basic traffic filtering via which of the following mechanisms?

- A. datagram scanning
- B. access lists
- C. stateful inspection
- D. state checking
- E. link progressing
- F. None of the choices.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In addition to deploying stateful firewall, you may setup basic traffic filtering on a more sophisticated router. As an example, on a Cisco IOS based router you may use ip access lists (ACL) to perform basic filtering on the network edge. Note that if they have denied too much traffic, something is obviously being too restrictive and you may want to reconfigure them.

QUESTION 139

Which of the following correctly describe the potential problem of deploying Wi-Fi Protected Access to secure your wireless network?

- A. potential compatibility problems with wireless network interface cards.
- B. potential compatibility problems with wireless access points.
- C. potential performance problems with wireless network interface cards.
- D. potential performance problems with wireless access points.
- E. None of the choices.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Wi-Fi Protected Access (WPA / WPA2) is a class of systems to secure wireless computer networks. It implements the majority of the IEEE 802.11i standard, and is designed to work with all wireless network interface cards (but not necessarily with first generation wireless access points).

QUESTION 140

The Federal Information Processing Standards (FIPS) were developed by:

- A. the United States Federal government
- B. ANSI
- C. ISO
- D. IEEE
- E. IANA
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Federal Information Processing Standards (FIPS) are publicly announced standards developed by the United States Federal government for use by all nonmilitary government agencies and by government contractors. Many FIPS standards are modified versions of standards used in the wider community.

QUESTION 141

The Federal Information Processing Standards (FIPS) are primarily for use by (Choose two.):

- A. all non-military government agencies
- B. US government contractors
- C. all military government agencies
- D. all private and public colleges in the US
- E. None of the choices.

Correct Answer: AB

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Federal Information Processing Standards (FIPS) are publicly announced standards developed by the United States Federal government for use by all nonmilitary government agencies and by government contractors. Many FIPS standards are modified versions of standards used in the wider community.

QUESTION 142

Sophisticated database systems provide many layers and types of security, including (Choose three.):

- A. Access control
- B. Auditing

- C. Encryption
- D. Integrity controls
- E. Compression controls

Correct Answer: ABCD
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Sophisticated database systems provide many layers and types of security, including Access control, Auditing, Authentication, Encryption and Integrity controls. An important procedure when evaluating database security is performing vulnerability assessments against the database. Database administrators or Information security administrators run vulnerability scans on databases to discover misconfiguration of controls within the layers mentioned above along with known vulnerabilities within the database software.

QUESTION 143

Which of the following refers to an important procedure when evaluating database security?

- A. performing vulnerability assessments against the database.
- B. performing data check against the database.
- C. performing dictionary check against the database.
- D. performing capacity check against the database system.
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Databases provide many layers and types of security, including Access control, Auditing, Authentication, Encryption and Integrity controls. An important procedure when evaluating database security is performing vulnerability assessments against the database. Database administrators or Information security administrators run vulnerability scans on databases to discover misconfiguration of controls within the layers mentioned above along with known vulnerabilities within the database software.

QUESTION 144

Which of the following refers to any authentication protocol that requires two independent ways to establish identity and privileges?

- A. Strong-factor authentication
- B. Two-factor authentication
- C. Dual-password authentication
- D. Two-passphrases authentication
- E. Dual-keys authentication
- F. Rich-factor authentication

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Two-factor authentication (T-FA) refers to any authentication protocol that requires two independent ways to establish identity and privileges. Common implementations of two-factor authentication use 'something you know' as one of the two factors, and use either 'something you have' or 'something you are' as the other factor. In fact, using more than one factor is also called strong authentication. On the other hand, using just one factor is considered by some weak authentication.

QUESTION 145

Common implementations of strong authentication may use which of the following factors in their authentication efforts (Choose three.):

- A. 'something you know'
- B. 'something you have'
- C. 'something you are'
- D. 'something you have done in the past on this same system'
- E. 'something you have installed on this same system'
- F. None of the choices.

Correct Answer: ABC
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Two-factor authentication (T-FA) refers to any authentication protocol that requires two independent ways to establish identity and privileges. Common implementations of two-factor authentication use 'something you know' as one of the two factors, and use either 'something you have' or 'something you are' as the other factor. In fact, using more than one factor is also called strong authentication. On the other hand, using just one factor is considered by some weak authentication.

QUESTION 146

Effective transactional controls are often capable of offering which of the following benefits (Choose four.):

- A. reduced administrative and material costs
- B. shortened contract cycle times
- C. enhanced procurement decisions
- D. diminished legal risk
- E. None of the choices.

Correct Answer: ABCD
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Transactional systems provide a baseline necessary to measure and monitor contract performance and provide a method for appraising efficiency against

possible areas of exposure. Effective transactional controls reduce administrative and material costs, shorten contract cycle times, enhance procurement decisions, and diminish legal risk.

QUESTION 147

In the context of physical access control, what is known as the process of verifying user identities?

- A. Authentication
- B. Authorization
- C. Accounting
- D. Encryption
- E. Compression
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Authentication is the process of verifying a user's claimed identity. It is based on at least one of these three factors: Something you know, Something you have, or Something you are.

QUESTION 148

Physical access controls are usually implemented based on which of the following means (Choose two.):

- A. mechanical locks
- B. guards
- C. operating systems
- D. transaction applications
- E. None of the choices.

Correct Answer: AB

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In physical security, access control refers to the practice of restricting entrance to authorized persons. Human means of enforcement include guard, bouncer, receptionist ... etc. Mechanical means may include locks and keys.

QUESTION 149

Fault-tolerance is a feature particularly sought-after in which of the following kinds of computer systems:

- A. desktop systems
- B. laptop systems
- C. handheld PDAs
- D. business-critical systems
- E. None of the choices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Fault-tolerance enables a system to continue operating properly in the event of the failure of some parts of it. It avoids total breakdown, and is particularly sought-after in high-availability environment full of business critical systems.

QUESTION 150

The technique of rummaging through commercial trash to collect useful business information is known as:

- A. Information diving
- B. Intelligence diving
- C. Identity diving
- D. System diving
- E. Program diving
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Dumpster diving in the form of information diving describes the practice of rummaging through commercial trash to find useful information such as files, letters, memos, passwords ...etc.

QUESTION 151

Which of the following refers to a primary component of corporate risk management with the goal of minimizing the risk of prosecution for software piracy due to use of unlicensed software?

- A. Software audit
- B. System audit
- C. Application System audit
- D. Test audit
- E. Mainframe audit
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Software audits are a component of corporate risk management, with the goal of minimizing the risk of prosecution for software piracy due to use of unlicensed software. From time to time internal or external audits may take a forensic approach to establish what is installed on the computers in an organization with the purpose of ensuring that it is all legal and authorized and to ensure that its process of processing transactions or events is correct.

QUESTION 152

In a security server audit, focus should be placed on (Choose two.):

- A. proper segregation of duties
- B. adequate user training
- C. continuous and accurate audit trail
- D. proper application licensing
- E. system stability
- F. performance and controls of the system
- G. None of the choices.

Correct Answer: AC

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 153

The purpose of a mainframe audit is to provide assurance that processes are being implemented as required, the mainframe is operating as it should, security is strong, and that procedures in place are working and are updated as needed. The auditor may accordingly make recommendations for improvement. Which of the following types of audit always takes high priority over the others? (Choose five.)

- A. System audit
- B. Application audit
- C. Software audit
- D. License audit
- E. Security server audit
- F. None of the choices.

Correct Answer:

Explanation

Explanation/Reference:

Correct Answer: ABCDE

Section: Protection of Information Assets

QUESTION 154

Talking about application system audit, focus should always be placed on (Choose five.)

- A. performance and controls of the system
- B. the ability to limit unauthorized access and manipulation
- C. input of data are processed correctly
- D. output of data are processed correctly
- E. changes to the system are properly authorized
- F. None of the choices.

Correct Answer:

Explanation

Explanation/Reference:

Correct Answer: ABCDE

Section: Protection of Information Assets

Talking about application system audit, focus should be placed on the performance and controls of the system, its ability to limit unauthorized access and manipulation, that input and output of data are processed correctly on the system, that any changes to the system are authorized, and that users have access to the system.

QUESTION 155

A successful risk-based IT audit program should be based on:

- A. an effective scoring system.
- B. an effective PERT diagram.
- C. an effective departmental brainstorm session.
- D. an effective organization-wide brainstorm session.
- E. an effective yearly budget.
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A successful risk-based IT audit program could be based on an effective scoring system. In establishing a scoring system, management should consider all relevant risk factors and avoid subjectivity. Auditors should develop written guidelines on the use of risk assessment tools and risk factors and review these guidelines with the audit committee.

QUESTION 156

The use of risk assessment tools for classifying risk factors should be formalized in your IT audit effort through:

- A. the use of risk controls.
- B. the use of computer assisted functions.
- C. using computer assisted audit technology tools.

- D. the development of written guidelines.
- E. None of the choices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A successful risk-based IT audit program could be based on an effective scoring system. In establishing a

scoring system, management should consider all relevant risk factors and avoid subjectivity. Auditors should develop written guidelines on the use of risk assessment tools and risk factors and review these guidelines with the audit committee.

QUESTION 157

Which of the following correctly describes the purpose of an Electronic data processing audit?

- A. to collect and evaluate evidence of an organization's information systems, practices, and operations.
- B. to ensure document validity.
- C. to verify data accuracy.
- D. to collect and evaluate benefits brought by an organization's information systems to its bottom line.
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An Electronic data processing (EDP) audit is an IT audit. It is the process of collecting and evaluating evidence of an organization's information systems, practices, and operations.

QUESTION 158

What should be done to determine the appropriate level of audit coverage for an organization's IT environment?

- A. determine the company's quarterly budget requirement.
- B. define an effective assessment methodology.
- C. calculate the company's yearly budget requirement.
- D. define an effective system upgrade methodology.
- E. define an effective network implementation methodology.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

To determine the appropriate level of audit coverage for the organization's IT environment, you must define an effective assessment methodology and provide objective information to prioritize the allocation of audit resources properly.

QUESTION 159

IS audits should be selected through a risk analysis process to concentrate on:

- A. those areas of greatest risk and opportunity for improvements.
- B. those areas of least risk and opportunity for improvements.
- C. those areas of the greatest financial value.
- D. areas led by the key people of the organization.
- E. random events.
- F. irregular events.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Audits are typically selected through a risk analysis process to concentrate on those areas of greatest risk and opportunity for improvements.

Audit topics are supposed to be chosen based on potential for cost savings and service improvements.

QUESTION 160

Your final audit report should be issued:

- A. after an agreement on the observations is reached.
- B. before an agreement on the observations is reached.
- C. if an agreement on the observations cannot be reached.
- D. without mentioning the observations.
- E. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Reporting can take the forms of verbal presentation, an issue paper or a written audit report summarizing observations and management's responses. After agreement is reached on the observations, a final report can be issued.

QUESTION 161

Well-written risk assessment guidelines for IS auditing should specify which of the following elements at the least (Choose four.)

- A. A maximum length for audit cycles.
- B. The timing of risk assessments.

- C. Documentation requirements.
- D. Guidelines for handling special cases.
- E. None of the choices.

Correct Answer: ABCD
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A well-written risk assessment guidelines should specify a maximum length for audit cycles based on the risk scores and the timing of risk assessments for each department or activity. There should be documentation requirements to support scoring decisions. There should also be guidelines for overriding risk assessments in special cases and the circumstances under which they can be overridden.

QUESTION 162

The ability of the internal IS audit function to achieve desired objectives depends largely on:

- A. the training of audit personnel
- B. the background of audit personnel
- C. the independence of audit personnel
- D. the performance of audit personnel
- E. None of the choices.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The ability of the internal audit function to achieve desired objectives depends largely on the independence of audit personnel. Top management should ensure that the audit department does not participate in activities that may compromise its independence.

QUESTION 163

In-house personnel performing IS audits should possess which of the following knowledge and/or skills (Choose two.):

- A. information systems knowledge commensurate with the scope of the IT environment in question
- B. sufficient analytical skills to determine root cause of deficiencies in question
- C. sufficient knowledge on secure system coding
- D. sufficient knowledge on secure platform development
- E. information systems knowledge commensurate outside of the scope of the IT environment in question

Correct Answer: AB
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Personnel performing IT audits should have information systems knowledge commensurate with the scope of the institution's IT environment. They should also possess sufficient analytical skills to determine the root cause of deficiencies.

QUESTION 164

A comprehensive IS audit policy should include guidelines detailing what involvement the internal audit team should have?

- A. in the development and coding of major OS applications.
- B. in the acquisition and maintenance of major WEB applications.
- C. in the human resource management cycle of the application development project.
- D. in the development, acquisition, conversion, and testing of major applications.
- E. None of the choices.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The audit policy should include guidelines detailing what involvement internal audit will have in the development, acquisition, conversion, and testing of major applications. Such a policy must be approved by top management for it to be effective.

QUESTION 165

For application acquisitions with significant impacts, participation of your IS audit team should be encouraged:

- A. early in the due diligence stage.
- B. at the testing stage.
- C. at the final approval stage.
- D. at the budget preparation stage.
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

For acquisitions with significant IT impacts, participation of IS audit is often necessary early in the due diligence stage as defined in the audit policy.

QUESTION 166

Which of the following should be seen as one of the most significant factors considered when determining the frequency of IS audits within your organization?

- A. The cost of risk analysis
- B. The income generated by the business function
- C. Resource allocation strategy
- D. The nature and level of risk

E. None of the choices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

You use a risk assessment process to describe and analyze the potential audit risks inherent in a given line of business. You should update such risk assessment at least annually to reflect changes. The level and nature of risk should be the most significant factors to be considered when determining the frequency of audits.

QUESTION 167

Properly planned risk-based audit programs are often capable of offering which of the following benefits?

- A. audit efficiency and effectiveness.
- B. audit efficiency only.
- C. audit effectiveness only.
- D. audit transparency only.
- E. audit transparency and effectiveness.
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Properly planned risk-based audit programs shall increase audit efficiency and effectiveness. The sophistication and formality of this kind of audit do vary a lot depending on the target's size and complexity.

QUESTION 168

The sophistication and formality of IS audit programs may vary significantly depending on which of the following factors?

- A. the target's management hands-on involvement.
- B. the target's location.
- C. the target's size and complexity.
- D. the target's budget.
- E. the target's head count.
- F. None of the choices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Properly planned risk-based audit programs shall increase audit efficiency and effectiveness. The sophistication and formality of this kind of audit do vary a lot depending on the target's size and complexity.

QUESTION 169

Which of the following is one most common way that spyware is distributed?

- A. as a trojan horse.
- B. as a virus.
- C. as an Adware.
- D. as a device driver.
- E. as a macro.
- F. None of the choices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

One of the most common ways that spyware is distributed is as a Trojan horse, bundled with a piece of desirable software that the user downloads off the Web or a peer-to-peer file-trading network. When the user installs the software, the spyware is installed alongside.

QUESTION 170

Which of the following is not a good tactic to use against hackers?

- A. Enticement
- B. Entrapment

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Enticement occurs after somebody has gained unlawful access to a system and then subsequently lured to a honey pot. Entrapment encourages the commitment of unlawful access. The latter is not a good tactic to use as it involves encouraging someone to commit a crime.

QUESTION 171

Creating which of the following is how a hacker can insure his ability to return to the hacked system at will?

- A. rootsec
- B. checksum
- C. CRC
- D. backdoors
- E. None of the choices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A backdoor refers to a generally undocumented means of getting into a system, mostly for programming and maintenance/troubleshooting needs. Most real world programs have backdoors. Creating backdoors is how a hacker can insure his ability to return to the hacked system at will.

QUESTION 172

A trojan horse simply cannot operate autonomously.

A. true

B. false

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

As a common type of Trojan horses, a legitimate software might have been corrupted with malicious code which runs when the program is used. The key is that the user has to invoke the program in order to trigger the malicious code. In other words, a trojan horse simply cannot operate autonomously. You would also want to know that most but not all trojan horse payloads are harmful - a few of them are harmless.

QUESTION 173

Which of the following refers to the collection of policies and procedures for implementing controls capable of restricting access to computer software and data files?

A. Binary access control

B. System-level access control

C. Logical access control

D. Physical access control

E. Component access control

F. None of the choices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Logical access control is about the use of a collection of policies, procedures, and controls to restrict access to computer software and data files.

Such control system should provide reasonable assurance that an organization's objectives are being properly achieved securely and reliably.

QUESTION 174

Which of the following is the GREATEST concern when an organization allows personal devices to connect to its network?

A. It is difficult to enforce the security policy on personal devices

B. Help desk employees will require additional training to support devices.

C. IT infrastructure costs will increase.

D. It is difficult to maintain employee privacy.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 175

Which of the following BEST ensures that effective change management is in place in an IS environment?

A. User authorization procedures for application access are well established.

B. User-prepared detailed test criteria for acceptance testing of the software.

C. Adequate testing was carried out by the development team.

D. Access to production source and object programs is well controlled.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 176

An IS auditor plans to review all access attempts to a video-monitored and proximity card-controlled communications room. Which of the following would be MOST useful to the auditor?

A. System electronic log

B. Security incident log

C. Manual sign-in and sign-out log

D. Alarm system with CCTV

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Reference: <https://www.slideshare.net/desmond.devendran/chap5-2007-cisa-review-course>

QUESTION 177

Which of the following is the BEST way to mitigate the risk of unintentional modifications associated with complex calculations in end-user computing (EUC)?

- A. Verify EUC results through manual calculations.
- B. Operate copies of EUC programs out of a secure library.
- C. Implement data integrity checks.
- D. Utilize an independent party to review the source calculations.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 178

An IS auditor has been asked to audit a complex system with computerized and manual elements. Which of the following should be identified FIRST?

- A. Manual controls
- B. System risks
- C. Programmed controls
- D. Input validation

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 179

The MOST appropriate person to chair the steering committee for an enterprise-wide system development should normally be the:

- A. project manager
- B. IS director
- C. executive level manager.
- D. business analyst

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 180

Which of the following activities is MOST important to consider when conducting IS audit planning?

- A. Results from previous audits are reviewed.
- B. Audit scheduling is based on skill set of audit team.
- C. Resources are allocated to areas of high risk.
- D. The audit committee agrees on risk rankings.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 181

A small startup organization does not have the resources to implement segregation of duties. Which of the following is the MOST effective compensating control?

- A. Rotation of log monitoring and analysis responsibilities
- B. Additional management reviews and reconciliations
- C. Third-party assessments
- D. Mandatory vacations

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets
Reference: <https://www.computerweekly.com/tip/Segregation-of-duties-Small-business-best-practices>

QUESTION 182

Which of the following BEST facilitates compliance with requirements mandating the security of confidential data?

- A. Classification of data
- B. Security awareness training
- C. Encryption of external data transmissions
- D. Standardized escalation protocols for breaches

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 183

An IS auditor is performing an audit of a large organization's operating system maintenance procedures. Which of the following findings presents the GREATEST risk?

- A. Some internal servers cannot be patched due to software incompatibility.

- B. The configuration management database is not up-to-date.
- C. Vulnerability testing is not performed on the development servers.
- D. Critical patches are applied immediately while others follow quarterly release cycles.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 184

Which of the following should occur EARLIEST in a business continuity management lifecycle?

- A. Defining business continuity procedures
- B. Identifying critical business processes
- C. Developing a training and awareness program
- D. Carrying out a threat and risk assessment

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 185

While performing a risk-based audit, which of the following would BEST enable an IS auditor to identify and categorize risk?

- A. Understanding the control framework
- B. Developing a comprehensive risk model
- C. Understanding the business environment
- D. Adopting qualitative risk analysis

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 186

Which of the following is a MAJOR benefit of using a wireless network?

- A. Faster network speed
- B. Stronger authentication
- C. Protection against eavesdropping
- D. Lower installation cost

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 187

Which of the following is appropriate when an IS auditor is conducting an exit meeting with senior management?

- A. Eliminate significant findings where audit and management agree on risk acceptance.
- B. Agree with senior management on the risk grading of the audit report.
- C. Document written responses from management along with an implementation plan.
- D. Escalate disputed recommendations to the audit committee.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 188

When conducting a follow-up of previous audit findings, an IS auditor is told by management that a recommendation to make security changes to an application has not been implemented. The IS auditor should FIRST determine whether:

- A. additional time to implement changes is needed.
- B. the associated risk is still relevant.
- C. the recommendation should be re-issued.
- D. the issue should be escalated.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 189

A new system development project is running late against a critical implementation deadline. Which of the following is the MOST important activity?

- A. Document last-minute enhancements.
- B. Perform user acceptance testing.
- C. Perform a pre-implementation audit.

D. Ensure that code has been reviewed.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 190

Which of the following actions should an organization's security policy require an employee to take upon finding a security breach?

- A. Report the incident to the manager immediately.
- B. Inform IS audit management immediately.
- C. Confirm the breach can be exploited.
- D. Devise appropriate countermeasures.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 191

The performance of an order-processing system can be measured MOST reliably by monitoring:

- A. input/request queue length.
- B. turnaround time of completed transactions.
- C. application and database servers' CPU load.
- D. heartbeats between server systems.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 192

In planning a major system development project, function point analysis would assist in:

- A. estimating the elapsed time of the project.
- B. estimating the size of a system development task.
- C. analyzing the functions undertaken by system users as an aid to job redesign.
- D. determining the business functions undertaken by a system or program.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 193

During an audit, the IS auditor finds that in many cases excessive rights were not removed from a system. Which of the following would be the auditor's BEST recommendation?

- A. IT security should regularly revoke excessive system rights.
- B. System administrators should ensure consistency of assigned rights.
- C. Line management should regularly review and request modification of access rights.
- D. Human resources should delete access rights of terminated employees.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 194

During an enterprise resource planning (ERP) post-implementation review, it was noted that operating costs have been significantly higher than anticipated. Which of the following should the organization have done to detect this issue?

- A. Updated the project charter as major changes occurred
- B. Conducted periodic user satisfaction surveys
- C. Performed an analysis of system usage
- D. Monitored financial key performance indicators (KPIs)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 195

Which of the following access rights in the production environment should be granted to a developer to maintain segregation of duties?

- A. Database administration
- B. Emergency support
- C. IT operations
- D. System administration

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 196

An IS auditor considering use of another auditor's workpapers should:

- A. rarely rely on the work of another auditor.
- B. determine that the workpapers were completed within the past month.
- C. determine that the auditee agrees with key issues in these workpapers.
- D. consider the appropriateness and sufficiency of the workpapers.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 197

Which of the following is the MOST important issue for an IS auditor to consider with regard to Voice-over IP (VoIP) communications?

- A. Continuity of service
- B. Homogeneity of the network
- C. Nonrepudiation
- D. Identity management

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 198

An organization with many desktop PCs is considering moving to a thin client architecture. Which of the following is the MAJOR advantage?

- A. Administrative security can be provided for the client.
- B. System administration can be better managed.
- C. The security of the desktop PC is enhanced.
- D. Desktop application software will never have to be upgraded.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 199

Which of the following would BEST assist senior management in evaluating IT performance as well as the alignment between corporate and IT strategic objectives?

- A. Enterprise architecture (EA)
- B. IT project value analysis
- C. Balanced scorecard
- D. Control self-assessment (CSA)

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 200

Which of the following should be the GREATEST concern to an IS auditor reviewing the information security framework of an organization?

- A. The information security policy has not been updated in the last two years.
- B. A list of critical information assets was not included in the information security policy.
- C. Senior management was not involved in the development of the information security policy.
- D. The information security policy is not aligned with regulatory requirements.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 201

The business case for an IS project has changed during the course of the project due to new requirements being added. What should be done NEXT?

- A. The project should go through the formal reapproval process.
- B. The changes to the business case should be documented in the project plan.
- C. Additional resources should be allocated to the project due to the new requirements.
- D. Project stakeholders should be notified of the changes.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 202

An organization has implemented a control to help ensure databases containing personal information will not be updated with online transactions that are incomplete due to connectivity issues. Which of the following information attributes is PRIMARILY addressed by this control?

- A. Integrity
- B. Confidentiality
- C. Availability
- D. Compliance

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 203

When planning an audit, it is acceptable for an IS auditor to rely on a third-party provider's external audit report on service level management when the:

- A. report was released within the last 12 months.
- B. scope and methodology meet audit requirements.
- C. service provider is independently certified and accredited.
- D. report confirms that service levels were not violated.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 204

When auditing a software development project, a review of which of the following will BEST verify that project work is adequately subdivided?

- A. Work breakdown structure
- B. Statement of work
- C. Scope statement
- D. Functional and technical design documents

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 205

A company uses a standard form to document and approve all changes in production programs. To ensure that the forms are properly authorized, which of the following is the MOST effective sampling method?

- A. Attribute
- B. Variable
- C. Discovery
- D. Monetary

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 206

An organization's business continuity plan should be:

- A. updated based on changes to personnel and environments.
- B. updated only after independent audit review by a third party.
- C. tested whenever new applications are implemented.
- D. tested after successful intrusions into the organization's hot site.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 207

During the review of a business process reengineering project, the PRIMARY concern of an IS auditor is to determine whether the new business model:

- A. is aligned with industry best practices.
- B. is aligned with organizational goals.
- C. leverages benchmarking results.
- D. meets its key performance measures.

Correct Answer: B

Explanation**Explanation/Reference:**

QUESTION 208

The PRIMARY purpose of reviewing the IT strategic plan is to identify risks that may:

- A. limit the ability to deliver customer requirements.
- B. limit the organization's ability to achieve its objectives.
- C. impact operational efficiency of the IT department.
- D. impact financial resourcing to implement the plan.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 209

An IS auditor finds that intellectual property is not being protected to the level specified in the organization's data classification and protection policy. The business owner is aware of this issue and chooses to accept the risk. Which of the following is the auditor's BEST course of action?

- A. Note the finding and request formal acceptance.
- B. Include the finding in the follow-up audit.
- C. Amend the data classification policy.
- D. Form a committee and further investigate the issue.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 210

Due to a recent business divestiture, an organization has limited IT resources to deliver critical projects. Reviewing the IT staffing plan against which of the following would BEST guide IT management when estimating resource requirements for future projects?

- A. Peer organization staffing benchmarks
- B. Budgeted forecast for the next financial year
- C. Human resources (HR) sourcing strategy
- D. Records of actual time spent on projects

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 211

During audit follow-up, an IS auditor finds that a control has been implemented differently than recommended. The auditor should:

- A. verify whether the control objectives are adequately addressed.
- B. compare the control to the action plan.
- C. report as a repeat finding.
- D. inform management about incorrect implementation.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 212

A source code repository should be designed to:

- A. provide automatic incorporation and distribution of modified code.
- B. prevent changes from being incorporated into existing code.
- C. provide secure versioning and backup capabilities for existing code.
- D. prevent developers from accessing secure source code.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 213

Which of the following could be determined by an entity-relationship diagram?

- A. Links between data objects
- B. How the system behaves as a consequence of external events
- C. How data are transformed as they move through the system
- D. Modes of behavior of data objects

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 214

Which of the following is a method to prevent disclosure of classified documents printed on a shared printer?

- A. Requiring a key code to be entered on the printer to produce hardcopy
- B. Producing a header page with classification level for printed documents
- C. Encrypting the data stream between the user's computer and the printer
- D. Using passwords to allow authorized users to send documents to the printer

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 215

To restore service at a large processing facility after a disaster, which of the following tasks should be performed FIRST?

- A. Launch the emergency action team.
- B. Inform insurance company agents.
- C. Contact equipment vendors.
- D. Activate the reciprocal agreement.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 216

A database is denormalized in order to:

- A. prevent loss of data.
- B. increase processing efficiency.
- C. ensure data integrity.
- D. save storage space.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 217

Electrical surge protectors BEST protect from the impact of:

- A. electromagnetic interference.
- B. power outages.
- C. sags and spikes
- D. reduced voltage.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 218

When removing a financial application system from production, which of the following is MOST important?

- A. Media used by the retired system has been sanitized.
- B. Data retained for regulatory purposes can be retrieved.
- C. End-user requests for changes are recorded and tracked.
- D. Software license agreements are retained.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 219

When planning an audit to assess application controls of a cloud-based system, it is MOST important for the IS auditor to understand the:

- A. policies and procedures of the business area being audited.
- B. business process supported by the system.
- C. availability reports associated with the cloud-based system.
- D. architecture and cloud environment of the system.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 220

During a security audit, which of the following is MOST important to review to ensure data confidentiality is managed?

- A. Access controls
- B. Data flows
- C. Access log monitoring
- D. Network configuration

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 221

An IS auditor is reviewing a contract for the outsourcing of IT facilities. If missing, which of the following should present the GREATEST concern to the auditor?

- A. Access control requirements
- B. Hardware configurations
- C. Perimeter network security diagram
- D. Help desk availability

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 222

An organization is currently replacing its accounting system. Which of the following strategies will BEST minimize risk associated with the loss of data integrity from the upgrade?

- A. Pilot implementation
- B. Functional integration testing
- C. Fallback contingency
- D. Parallel implementation

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 223

Which of the following would be the BEST performance indicator for the effectiveness of an incident management program?

- A. Incident alert meantime
- B. Average time between incidents
- C. Number of incidents reported
- D. Incident resolution meantime

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 224

An IS auditor is reviewing the performance outcomes of controls in an agile development project. Which of the following would provide the MOST relevant evidence for the auditor to consider?

- A. Progress report of outstanding work
- B. Product backlog
- C. Number of failed builds
- D. Composition of the scrum team

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 225

An IS auditor performing an audit of backup procedures observes that backup tapes are picked up weekly and stored offsite at a third-party hosting facility. Which of the following recommendations would be the BEST way to protect the data on the backup tapes?

- A. Ensure that data is encrypted before leaving the facility.
- B. Ensure that the transport company obtains signatures for all shipments.
- C. Confirm that data is transported in locked tamper-evident containers.
- D. Confirm that data transfers are logged and recorded.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 226

During an audit of a financial application, it was determined that many terminated users' accounts were not disabled. Which of the following should be the IS auditor's NEXT step?

- A. Perform a review of terminated users' account activity.
- B. Conclude that IT general controls are ineffective.
- C. Communicate risks to the application owner.
- D. Perform substantive testing of terminated users' access rights.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 227

An IS auditor finds the log management system is overwhelmed with false positive alerts. The auditor's BEST recommendation would be to:

- A. recruit more monitoring personnel.
- B. fine tune the intrusion detection system (IDS).
- C. reduce the firewall rules.
- D. establish criteria for reviewing alerts.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 228

Which of the following is the BEST reason for an organization to develop a business continuity plan?

- A. To develop a detailed description of information systems and processes
- B. To identify the users of information systems and processes
- C. To avoid the costs resulting from the failure of key systems and processes
- D. To establish business unit prioritization of systems, projects, and strategies

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets
Reference: <http://www.isaca.org/Knowledge-Center/Research/ResearchDeliverables/Pages/Business-Continuity-Management-Audit-Assurance-Program.aspx>

QUESTION 229

One advantage of managing an entire collection of projects as a portfolio is that it highlights the need to:

- A. identify dependencies between projects.
- B. inform users about all ongoing projects.
- C. manage the risk of each individual project.
- D. manage the quality of each project.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 230

Which of the following should be the MOST important consideration when determining which information system application to audit?

- A. Cost-benefit analysis
- B. Available resources
- C. Business impact analysis
- D. Newly implemented systems

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 231

In an organization that has a staff-rotation policy, the MOST appropriate access control model is:

- A. role-based.
- B. discretionary.
- C. mandatory.
- D. lattice-based.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 232

Which of the following should be an IS auditor's BEST recommendation to prevent installation of unlicensed software on employees' company-provided devices?

- A. Enforce audit logging of software installation activities.
- B. Restrict software installation authority to administrative users only.

- C. Implement software blacklisting.
- D. Remove unlicensed software from end-user devices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 233

Which of the following is the MOST reliable way for an IS auditor to evaluate the operational effectiveness of an organization's data loss prevention (DLP) controls?

- A. Verify that confidential files cannot be transmitted to a personal USB device.
- B. Conduct interviews to identify possible data protection vulnerabilities.
- C. Review data classification levels based on industry best practice.
- D. Verify that current DLP software is installed on all computer systems.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 234

When protecting the confidentiality of information assets, the MOST effective control practice is the:

- A. awareness training of personnel on regulatory requirements.
- B. enforcement of a need-to-know access control philosophy.
- C. utilization of a dual-factor authentication mechanism.
- D. configuration of read-only access to all users.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 235

Which of the following is the MOST effective method of destroying sensitive data stored on electronic media?

- A. Physical destruction
- B. Degaussing
- C. Random character overwrite
- D. Low-level formatting

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Reference: <https://www.isaca.org/Journal/archives/2010/Volume-6/Pages/An-Introduction-to-Digital-Records-Management.aspx>

QUESTION 236

Email required for business purposes is being stored on employees' personal devices. Which of the following is an IS auditor's BEST recommendation?

- A. Implement an email containerization solution on personal devices
- B. Prohibit employees from storing company email on personal devices.
- C. Ensure antivirus to utilize passwords on personal devices.
- D. Require employees to utilize passwords on personal devices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 237

When designing metrics for information security, the MOST important consideration is that the metrics:

- A. provide actionable data.
- B. apply to all business units.
- C. are easy to understand.
- D. track trends over time.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Reference: <https://m.isaca.org/Journal/archives/2016/volume-6/Documents/Journal-volume-6-2016.pdf>

QUESTION 238

Which of the following IS functions can be performed by the same group or individual while still providing the proper segregation of duties?

- A. Computer operations and application programming
- B. Database administration and computer operations

- C. Security administration and application programming
- D. Application programming and systems analysis

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Reference: <https://www.isaca.org/Journal/archives/2016/volume-3/Pages/implementing-segregation-of-duties.aspx>

QUESTION 239

In a high-volume, real-time system, the MOST effective technique by which to continuously monitor and analyze transaction processing is:

- A. integrated test facility (ITF).
- B. embedded audit modules.
- C. parallel simulation.
- D. transaction tagging.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 240

An organization wants to reuse company-provided smartphones collected from staff leaving the organization. Which of the following would be the BEST recommendation?

- A. The memory cards of the smartphones should be replaced.
- B. Smartphones should not be reused, but physically destroyed.
- C. Data should be securely deleted from the smartphones.
- D. The SIM card and telephone number should be changed.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 241

Which of the following should an IS auditor expect to find in an organization's information security policies?

- A. Authentication requirements
- B. Asset provisioning lifecycle
- C. Security configuration settings
- D. Secure coding procedures

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 242

Which of the following requirements in a document control standard would provide nonrepudiation to digitally signed legal documents?

- A. All digital signatures must include a hashing algorithm.
- B. All digitally signed documents must be stored in an encrypted database.
- C. All documents requiring digital signatures must be signed by both the customer and a witness.
- D. Only secure file transfer protocol (SFTP) may be used for digitally signed documentation.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 243

Which of the following would MOST likely impact the integrity of a database backup?

- A. Record fields contain null information
- B. Open database files during backup
- C. Relational database model used
- D. Backing up the database to an optical disk

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 244

When conducting a post-implementation review, which of the following is the BEST way to determine whether the value from an IT project has been achieved?

- A. Calculate the return on investment (ROI).
- B. Interview stakeholders.
- C. Conduct an earned value analysis (EVA).

D. Survey end users.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 245

Reviewing project plans and status reports throughout the development life cycle will:

- A. eliminate the need to perform a risk assessment.
- B. postpone documenting the project's progress until the final phase.
- C. guarantee that the project will meet its intended deliverables.
- D. facilitate the optimal use of resources over the life of the project.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 246

Which of the following is the PRIMARY reason an IS auditor should discuss observations with management before delivering a final report?

- A. Identify business risks associated with the observations.
- B. Assist the management with control enhancements.
- C. Record the proposed course of corrective action.
- D. Validate the audit observations.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 247

Which of the following is the MOST effective control to minimize the risk of cross-site scripting (XSS)?

- A. Periodic vulnerability assessments
- B. Secure coding practices
- C. Network intrusion prevention system
- D. Web firewall policy

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 248

During a follow-up audit, an IS auditor finds that the auditee has updated virus scanner definitions without adopting the original audit recommendation to increase the frequency of using the scanner. The MOST appropriate action for the auditor is to:

- A. prepare a follow-up audit report reiterating the recommendation.
- B. escalate the issue to senior management.
- C. modify the audit opinion based on the new information available.
- D. conclude that the residual risk is beyond tolerable levels of risk.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 249

When developing a business continuity plan (BCP), business unit management's involvement is MOST important during the:

- A. performance of a business impact analysis (BIA).
- B. development of business recovery procedures.
- C. implementation of a document repository.
- D. performance of an IT risk assessment.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 250

The final acceptance testing of a new application system should be the responsibility of the:

- A. IS audit team.
- B. user group
- C. IS management
- D. quality assurance team

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 251

Which of the following is MOST important when an organization contracts for the long-term use of a custom- developed application?

- A. Documented coding standards
- B. Error correction management
- C. Contract renewal provisions
- D. Escrow clause

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 252

Which should be reviewed FIRST by an IS auditor to ensure that data is being secured appropriately for an application?

- A. Data classification
- B. Data encryption
- C. Data access
- D. Data storage

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets
Data classification is necessary to provide proper access rights to the users. If you do not classify data according to their sensitivity and importance to the business, you cannot apply proper access rules to them. Data owners are responsible for defining access rules. The data classification process starts with the process of establishing ownership of data. This process also helps to prepare data dictionary

QUESTION 253

Which of the following would a digital signature MOST likely prevent?

- A. Corruption
- B. Unauthorized change
- C. Repudiation
- D. Disclosure

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets
The main reason of using digital signature is to ensure message integrity.it also helps to ensure authenticity and non-repudiation of the message. A digital signature can never ensure the confidentiality of data

QUESTION 254

A computer program used by multiple departments has data quality issues. There is no agreement as to who should be responsible for corrective action. Which of the following is an IS auditor's BEST course of action?

- A. Recommend the IT department be assigned data cleansing responsibility.
- B. Modify the program to automatically cleanse the data and close the issue.
- C. Assign responsibility to the primary department using the program.
- D. Note the disagreement and recommend establishing data governance.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 255

An IS auditor has just completed a physical access review of the organization's primary data center. Which of the following weaknesses should be of MOST concern?

- A. Metal keys are used for access.
- B. Backups of video cameras are corrupt.
- C. There is no mantrap at the main door.
- D. There is no manual logging for visitors.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 256

An IS auditor's PRIMARY concern about a business partner agreement for the exchange of electronic information should be to determine whether there is:

- A. a clause that addresses the audit of shared systems.
- B. evidence of review and approval by each partner's legal department.

- C. an information classification framework.
- D. appropriate control and responsibility defined for each partner.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The overall purpose of using a formal information classification scheme is to ensure proper handling based on the information content and context. Context refers to the usage of information. Two major risks are present in the absence of an information classification scheme. The first major risk is that information will be mishandled. The second major risk is that without an information classification scheme, all of the organization's data may be subject to scrutiny during legal proceedings. The information classification scheme safeguards knowledge. Failure to implement a records and data classification scheme leads to disaster

QUESTION 257

The BEST reason for implementing a virtual private network (VPN) is that it:

- A. eases the implementation of data encryption.
- B. allows for public use of private networks.
- C. enables use of existing hardware platforms.
- D. allows for private use of public networks.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Virtual private networks (VPNs) connect remote users over an insecure public network such as the Internet. The connection is virtual because it is temporary with no physical presence. VPN technology is cost-effective and highly flexible. A VPN creates an encrypted tunnel to securely pass data as follows:

Between two machines (host-host)



From a machine to a network (host-gateway)



From one network to another network (gateway-gateway)



QUESTION 258

In an annual audit cycle, the audit of an organization's IT department resulted in many findings. Which of the following would be the MOST important consideration when planning the next audit?

- A. Limiting the review to the deficient areas
- B. Verifying that all recommendations have been implemented
- C. Postponing the review until all of the findings have been rectified
- D. Following up on the status of all recommendations

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 259

An IS auditor is conducting a follow-up internal IS audit and determines that several recommendations from the prior year have not been implemented. Which of the following should be the auditor's FIRST course of action?

- A. Evaluate the recommendations in context of the current IT environment.
- B. Continue the audit and disregard prior audit recommendations.
- C. Request management implement recommendations from the prior year.

D. Add unimplemented recommendations as findings for the new audit.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 260

Which of the following controls BEST ensures appropriate segregation of duties within an accounts payable department?

- A. Ensuring that audit trails exist for transactions
- B. Restricting access to update programs to accounts payable staff only
- C. Restricting program functionality according to user security profiles
- D. Including the creator's user ID as a field in every transaction record created

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 261

When reviewing the process by which a contract for the outsourcing of various IT functions was completed, an IS auditor would ensure that the successful contractor:

- A. has eliminated the risks of outsourcing.
- B. maintains an internal audit function.
- C. requires a confidentiality agreement to be signed by all employees.
- D. was selected according to established business criteria.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 262

Which of the following would be the PRIMARY benefit of replacing physical keys with an electronic entry system for a data center?

- A. Creates an audit trail
- B. Enables data mining
- C. Ensures compliance
- D. Reduces cost

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 263

Which of the following is the BEST way to determine if IT is delivering value to the business?

- A. Distribute surveys to various end users of IT services.
- B. Interview key IT managers and service providers.
- C. Review IT service level agreement (SLA) metrics.
- D. Analyze downtime frequency and duration.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A service level agreement (SLA) is a written document, which officially describe the details of services, in non- technical terms, provided by the IT department (internal or external) to its customers. The aim of SLA is to maintain and improve the customer satisfaction to an agreed level.

QUESTION 264

Following an IS audit recommendation, all Telnet and File Transfer Protocol (FTP) connections have been replaced by Secure Socket Shell (SSH) and Secure File Transfer Protocol (SFTP). Which risk treatment approach has the organization adopted?

- A. Acceptance
- B. Mitigation
- C. Avoidance
- D. Transfer

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 265

Which of the following would be the BEST way to address segregation of duties issues in an organization with budget constraints?

- A. Perform an independent audit.

- B. Rotate job duties periodically.
- C. Implement compensating controls.
- D. Hire temporary staff.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 266

In a large organization, IT deadlines on important projects have been missed because IT resources are not prioritized properly. Which of the following is the BEST recommendation to address this problem?

- A. Implement project portfolio management.
- B. Implement an integrated resource management system.
- C. Implement a comprehensive project scorecard.
- D. Revisit the IT strategic plan.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 267

Which of the following would be MOST useful when analyzing computer performance?

- A. Report of off-peak utilization and response time
- B. Tuning of system software to optimize resource usage
- C. Operations report of user dissatisfaction with response time
- D. Statistical metrics measuring capacity utilization

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 268

When migrating critical systems to a cloud provider, the GREATEST data security concern for an organization would be that data from different clients may be:

- A. subject to different service level agreements (SLAs) for disaster recovery.
- B. subject to varying government compliance regulations.
- C. improperly separated from each other.
- D. requested during a legal discovery process.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 269

As part of a post-implementation review, the BEST way to assess the realization of outcomes is by:

- A. obtaining feedback from the user community.
- B. performing a comprehensive risk analysis.
- C. evaluating the actual performance of the system.
- D. comparing the business case benefits to the achieved benefits.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 270

A recent audit identified duplicate software licenses and technologies. Which of the following would be MOST helpful to prevent this type of duplication in the future?

- A. Centralizing IT procurement and approval practices
- B. Updating IT procurement policies and procedures
- C. Conducting periodic inventory reviews
- D. Establishing a project management office

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 271

An IS auditor finds multiple situations where the help desk resolved security incidents without notifying IT security as required by policy. Which of the following is the BEST audit recommendation?

- A. Display the incident response hotline in common areas.

- B. Have IT security review problem management policy.
- C. Reinforce the incident escalation process.
- D. Redesign the help desk reporting process.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 272

After threats to a data center are identified, an IS auditor would expect management to FIRST:

- A. recommend required actions to executive management.
- B. discuss risk management practices with neighboring firms.
- C. implement procedures to address all identified threats.
- D. establish and quantify the potential effects if each threat occurs.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 273

During a review of information security procedures for disabling user accounts, an IS auditor discovers that IT is only disabling network access for terminated employees. IT management maintains if terminated users cannot access the network, they will not be able to access any applications. Which of the following is the GREATEST risk associated with application access?

- A. Unauthorized access to data
- B. Inability to access data
- C. Lack of segregation of duties
- D. Loss of non-repudiation

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 274

Adopting a service-oriented architecture would MOST likely:

- A. inhibit integration with legacy systems.
- B. compromise application software security.
- C. facilitate connectivity between partners.
- D. streamline all internal processes.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 275

Which of the following is the BEST data integrity check?

- A. Counting the transactions processed per day
- B. Performing a sequence check
- C. Tracing data back to the point of origin
- D. Preparing and running test data

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 276

An IS auditor seeks assurance that a new process for purging transactions does not have a detrimental impact on the integrity of a database. This could be achieved BEST by analyzing the:

- A. database structure.
- B. design of triggers.
- C. results of the process in a test environment.
- D. entity relationship diagram of the database.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 277

Organization A has a Software as a Service Agreement (SaaS) with Organization B. The software is vital to Organization A. Which of the following would provide the GREATEST assurance that the application can be recovered in the event of a disaster?

- A. Organization B is responsible for disaster recovery and held accountable for interruption of service.

- B. Organization A has a source code escrow agreement and hardware procurement provisions for disaster recovery purposes.
- C. Organization B has a disaster recovery plan included in its contract and allows oversight by Organization A.
- D. Organization A buys disaster insurance to recuperate losses in the event of a disaster.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 278

Which of the following should be of MOST concern to an IS auditor during the review of a quality management system?

- A. The quality management system includes training records for IT personnel.
- B. There are no records to document actions for minor business processes.
- C. Important quality checklists are maintained outside the quality management system.
- D. Indicators are not fully represented in the quality management system.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 279

An organization has begun using social media to communicate with current and potential clients. Which of the following should be of PRIMARY concern to the auditor?

- A. Using a third-party provider to host and manage content
- B. Lack of guidance on appropriate social media usage and monitoring
- C. Negative posts by customers affecting the organization's image
- D. Reduced productivity of staff using social media

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 280

An IS auditor should ensure that an application's audit trail:

- A. has adequate security
- B. does not impact operational efficiency.
- C. is accessible online.
- D. logs all database records.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 281

As part of an audit response, an auditee has concerns with the recommendations and is hesitant to implement them. Which of the following would be the BEST course of action for the IS auditor?

- A. Accept the auditee's response and perform additional testing.
- B. Conduct further discussions with the auditee to develop a mitigation plan.
- C. Suggest hiring a third-party consultant to perform a current state assessment.
- D. Issue a final report without including the opinion of the auditee.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 282

Which of the following is the FIRST step in initiating a data classification program?

- A. Risk appetite assessment
- B. Inventory of data assets
- C. Assignment of data ownership
- D. Assignment of sensitivity levels

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The data classification process starts with the process of establishing ownership of data. This process also helps to prepare data dictionary

QUESTION 283

Which of the following should be used to assess the level of security required to protect information on a corporate network?

- A. Data classification

- B. Business intelligence
- C. Access rights
- D. Access control matrix

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 284

Which of the following is the MOST important difference between end-user computing (EUC) applications and traditional applications?

- A. Traditional application documentation is typically less comprehensive than EUC application documentation.
- B. Traditional applications require roll-back procedures whereas EUC applications do not.
- C. Traditional applications require periodic patching whereas EUC applications do not.
- D. Traditional application input controls are typically more robust than EUC application input controls.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 285

Which of the following is the MOST significant risk when an application uses individual end user accounts to access the underlying database?

- A. User accounts may remain active after a termination.
- B. Multiple connects to the database are used and slow the process.
- C. Application may not capture a complete audit trail.
- D. Users may be able to circumvent application controls.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 286

An IS auditor is assessing the results of an organization's post-implementation review of a newly developed information system. Which of the following should be the auditor's MAIN focus?

- A. The procurement contract has been closed.
- B. Lessons learned have been identified.
- C. The disaster recovery plan has been updated.
- D. Benefits realization analysis has been completed.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 287

Which of the following is the MOST effective way to maintain network integrity when using mobile devices?

- A. Perform network reviews.
- B. Implement network access control.
- C. Implement outbound firewall rules.
- D. Review access control lists.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 288

Which of the following should be an IS auditor's PRIMARY focus when developing a risk-based IS audit program?

- A. Business plans
- B. Business processes
- C. IT strategic plans
- D. Portfolio management

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 289

During a follow-up audit, an IS auditor discovers that a recommendation has not been implemented. However, the auditee has implemented a manual workaround that addresses the identified risk, through far less efficiency than the recommended action would. Which of the following would be the auditor's BEST course of action?

- A. Notify management that the risk has been addressed and take no further action.

- B. Escalate the remaining issue for further discussion and resolution.
- C. Note that the risk has been addressed and notify management of the inefficiency.
- D. Insist to management that the original recommendation be implemented.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 290

An organization is replacing its financial processing system. To help ensure that transactions in the new system are processed accurately, which of the following is MOST appropriate?

- A. Compare year-to-date balances between the systems.
- B. Reconcile results of parallel processing.
- C. Document and test internal controls over the conversion.
- D. Review data file conversion procedures.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 291

Which of the following methods would be MOST effective in verifying that all changes have been authorized?

- A. Reconciling problem tickets with authorized change control entries
- B. Reconciling reports of changes in production libraries to authorized change log entries
- C. Validating authorized change log entries with individual(s) who promoted into production
- D. Reconciling reports of changes in development libraries to supporting documentation

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 292

During the evaluation of a firm's newly established whistleblower system, an auditor notes several findings. Which of the following should be the auditor's GREATEST concern?

- A. New employees have not been informed of the whistleblower policy.
- B. The whistleblower's privacy is not protected.
- C. The whistleblower system does not track the time and date of submission.
- D. The whistleblower system is only available during business hours.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 293

An organization has established three IT processing environments: development, test, and production. The MAJOR reason for separating the development and test environments is to:

- A. obtain segregation of duties between IT staff and end users.
- B. limit the users' access rights to the test environment.
- C. perform testing in a stable environment.
- D. protect the programs under development from unauthorized testing.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 294

An organization allows its employees to use personal mobile devices for work. Which of the following would BEST maintain information security without compromising employee privacy?

- A. Partitioning the work environment from personal space on devices
- B. Preventing users from adding applications
- C. Restricting the use of devices for personal purposes during working hours
- D. Installing security software on the devices

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 295

Which of the following is a reason for implementing a decentralized IT governance model?

- A. Standardized controls and economies of scale

- B. IT synergy among business units
- C. Greater consistency among business units
- D. Greater responsiveness to business needs

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 296

The use of symmetric key encryption controls to protect sensitive data transmitted over a communications network requires that:

- A. primary keys for encrypting the data be stored in encrypted form.
- B. encryption keys be changed only when a compromise is detected at both ends.
- C. encryption keys at one end be changed on a regular basis.
- D. public keys be stored in encrypted form.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 297

A purpose of project closure is to determine the:

- A. potential risks affecting the quality of deliverables.
- B. lessons learned for use in future projects.
- C. project feasibility requirements
- D. professional expertise of the project manager.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 298

When providing a vendor with data containing personally identifiable information (PII) for offsite testing, the data should be:

- A. current
- B. encrypted.
- C. sanitized.
- D. backed up.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 299

Which of the following should be the PRIMARY basis for prioritizing follow-up audits?

- A. Complexity of management's actions plans
- B. Recommendation from executive management
- C. Audit cycle defined in the audit plan
- D. Residual risk from the findings of previous audits

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 300

An IS auditor is reviewing the results of a business process improvement project. Which of the following should be performed FIRST?

- A. Evaluate control gaps between the old and the new processes.
- B. Develop compensating controls.
- C. Document the impact of control weaknesses in the process.
- D. Ensure that lessons learned during the change process are documented.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 301

Which of the following controls can BEST detect accidental corruption during transmission of data across a network?

- A. Sequence checking
- B. Parity checking
- C. Symmetric encryption
- D. Check digit verification

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Parity check is used to detect transmission errors in the data. When a parity check is applied to a single character, it is called vertical or column check. In addition, if a parity check is applied to all the data it is called vertical or row check. By using both types of parity check simultaneously can greatly increase the error detection possibility, which may not be possible when only one type of parity check is used.

QUESTION 302

An IS auditor is asked to identify risk within an organization's software development project. The project manager tells the auditor that an agile development methodology is being used to minimize the lengthy development process. Which of the following would be of GREATEST concern to the auditor?

- A. Each team does its own testing.
- B. The needed work has not yet been fully identified.
- C. Some of the developers have not attended recent training.
- D. Elements of the project have not been documented.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 303

Which of the following must be in place before an IS auditor initiates audit follow-up activities?

- A. A heat map with the gaps and recommendations displayed in terms of risk
- B. A management response in the final report with a committed implementation date
- C. Supporting evidence for the gaps and recommendations mentioned in the audit report
- D. Available resources for the activities included in the action plan

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 304

To maintain the confidentiality of information moved between office and home on removable media, which of the following is the MOST effective control?

- A. Mandatory file passwords
- B. Security awareness training
- C. Digitally signed media
- D. Data encryption

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 305

An organization transmits large amounts of data from one internal system to another. The IS auditor is reviewing the quality of the data at the originating point. Which of the following should the auditor verify FIRST?

- A. The data has been encrypted.
- B. The data transformation is accurate.
- C. The data extraction process is completed.
- D. The source data is accurate.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 306

An IS auditor intends to accept a management position in the data processing department within the same organization. However, the auditor is currently working on an audit of a major application and has not yet finished the report. Which of the following would be the BEST step for the IS auditor to take?

- A. Start in the position and inform the application owner of the job change.
- B. Start in the position immediately.
- C. Disclose this issue to the appropriate parties.
- D. Complete the audit without disclosure and then start in the position.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 307

Which of the following would BEST describe an audit risk?

- A. The company is being sued for false accusations.
- B. The financial report may contain undetected material errors.

- C. Key employees have not taken vacation for 2 years.
- D. Employees have been misappropriating funds.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 308

During an audit of a reciprocal disaster recovery agreement between two companies, the IS auditor would be MOST concerned with the:

- A. allocation of resources during an emergency.
- B. maintenance of hardware and software compatibility.
- C. differences in IS policies and procedures.
- D. frequency of system testing.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 309

While planning a review of IT governance, the IS auditor is MOST likely to:

- A. examine audit committee minutes for IS-related matters and their control.
- B. obtain information about the framework of control adopted by management.
- C. assess whether business process owner responsibilities are consistent across the organization.
- D. review compliance with policies and procedures issued by the board of directors.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 310

What is the MOST difficult aspect of access control in a multiplatform, multiple-site client/server environment?

- A. Creating new user IDs valid only on a few hosts
- B. Maintaining consistency throughout all platforms
- C. Restricting a local user to necessary resources on a local platform
- D. Restricting a local user to necessary resources on the host server

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 311

Which of the following cloud deployment models would BEST meet the needs of a startup software development organization with limited initial capital?

- A. Private
- B. Public
- C. Community
- D. Hybrid

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 312

An IS auditor is reviewing documentation of application systems change control and identifies several patches that were not tested before being put into production. Which of the following is the MOST significant risk from this situation?

- A. Developer access to production
- B. Lack of system integrity
- C. Outdated system documentation
- D. Loss of application support

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 313

Which of the following would BEST help ensure information security is effective following the outsourcing of network operations?

- A. Test security controls periodically.
- B. Review security key performance indicators (KPIs).
- C. Establish security service level agreements (SLAs).
- D. Appoint a security service delivery monitoring manager.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 314

As part of a mergers and acquisitions activity, an acquiring organization wants to consolidate data and system from the organization being acquired into existing systems. To ensure the data is relevant, the acquiring organization should:

- A. obtain data quality software.
- B. define data quality requirements based on business needs.
- C. automate the process of data collection and cleaning.
- D. implement a data warehouse solution.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 315

The business owner's approval of software changes being moved into production is PRIMARILY necessary to:

- A. ensure that an application functionality requirement is satisfied.
- B. prevent unauthorized access to data.
- C. inform management of deployments of new functionality.
- D. confirm there is a process to control system changes.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 316

A warehouse employee of a retail company has been able to conceal the theft of inventory items by entering adjustments of either damaged or lost stock items to the inventory system. Which control would have BEST prevented this type of fraud in a retail environment?

- A. An edit check for the validity of the inventory transaction
- B. Separate authorization for input of transactions
- C. Unscheduled audits of lost stock lines
- D. Statistical sampling of adjustment transactions

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 317

Which of the following controls will MOST effectively detect inconsistent records resulting from the lack of referential integrity in a database management system?

- A. Concurrent access controls
- B. Incremental data backups
- C. Performance monitoring tools
- D. Periodic table link checks

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 318

Which of the following is MOST appropriate to prevent unauthorized retrieval of confidential information stored in a business application system?

- A. Apply single sign-on for access control.
- B. Enforce an internal data access policy.
- C. Enforce the use of digital signatures.
- D. Implement segregation of duties.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 319

Which of the following is the MOST effective way for an organization to protect against data leakage?

- A. Conduct periodic security awareness training.
- B. Limit employee Internet access.
- C. Review firewall logs for anomalies.
- D. Develop a comprehensive data loss prevention policy.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 320

Which of the following would BEST help to support an auditor's conclusion about the effectiveness of an implemented data classification program?

- A. Detailed data classification scheme
- B. Access rights provisioned according to scheme
- C. Business use cases and scenarios
- D. Purchase of information management tools

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 321

An organization is considering using production data for testing a new application's functionality. Which of the following data protection techniques would BEST ensure that personal data cannot be inadvertently recovered in test environments while also reducing the need for strict confidentiality of the data?

- A. Data anonymization
- B. Data minimization
- C. Data normalization
- D. Data encryption

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 322

Disaster recovery planning for network connectivity to a hot site over a public-switched network would be MOST likely to include:

- A. minimizing the number of points of presence
- B. contracts for acquiring new leased lines
- C. reciprocal agreements with customers of that network
- D. redirecting private virtual circuits

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 323

Which of the following privacy principles ensures data controllers do not use personal data unintended ways that breach protection of data subjects?

- A. Data retention
- B. Adequacy
- C. Accuracy
- D. Purpose limitation

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 324

An organization's software developers need access to personally identifiable information (PII) stored in a particular data format. Which of the following is the BEST way to protect this sensitive information while allowing the developers to use it in development and test environments?

- A. Data masking
- B. Data encryption
- C. Data tokenization
- D. Data abstraction

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 325

As part of business continuity planning, which of the following is MOST important to include in a business impact analysis (BIA)?

- A. Define a risk appetite.
- B. Assess risk of moving significant applications to the cloud.
- C. Assess recovery scenarios.
- D. Assess threats to the organization.

Correct Answer: D

Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 326

Which of the following is the MOST important reason for updating and retesting a business continuity plan (BCP)?

- A. Staff turnover
- B. Emerging technology
- C. Significant business change
- D. Matching industry best practices

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 327

When developing a business continuity plan (BCP), which of the following should be performed FIRST?

- A. Develop business continuity training
- B. Classify operations
- C. Conduct a business impact analysis (BIA)
- D. Establish a disaster recovery plan (DRP)

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 328

An organization has outsourced its data leakage monitoring to an Internet service provider (ISP). Which of the following is the BEST way for an IS auditor to determine the effectiveness of this service?

- A. Verify the ISP has staff to deal with data leakage
- B. Review the ISP's external audit report
- C. Review the data leakage clause in the SLA
- D. Simulate a data leakage incident

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 329

Which of the following would be of GREATEST concern to an IS auditor reviewing a critical spreadsheet during a financial audit?

- A. Periodic access reviews are manually performed.
- B. Changes to the file are not always documented.
- C. Access requests are manually processed.
- D. A copy of the current validated file is not available.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 330

Which of the following activities is MOST important in determining whether a test of a disaster recovery plan (DRP) has been successful?

- A. Evaluating participation by key personnel
- B. Testing at the backup data center
- C. Analyzing whether predetermined test objectives were met
- D. Testing with offsite backup files

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 331

Which of the following should be the FIRST step when conducting an IT risk assessment?

- A. Assess vulnerabilities
- B. Identify assets to be protected
- C. Evaluate controls in place
- D. Identify potential threats

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 332

To develop a robust data security program, the FIRST course of action should be to:

- A. implement monitoring controls
- B. implement data loss prevention (DLP) controls
- C. perform an inventory of assets
- D. interview IT senior management

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 333

An IS auditor has been asked to participate in the creation of an organization's formal business continuity program. Which of the following would impair auditor independence?

- A. Developing disaster recovery test scenarios
- B. Determining system criticality
- C. Facilitating the business impact analysis (BIA)
- D. Participating on the business continuity committee

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 334

When is the BEST time to commence continuity planning for a new application system?

- A. Immediately after implementation
- B. Just prior to the handover to the system maintenance group
- C. During the design phase
- D. Following successful user testing

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 335

An IS auditor is performing a consulting engagement and needs to make a recommendation for securing all doors to a data center to prevent unauthorized access. Which of the following access control techniques would be MOST difficult for an intruder to compromise?

- A. Dead-man door and swipe card
- B. Smart card and numeric keypad
- C. USB token and password
- D. Biometrics and PIN

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 336

Invoking a business continuity plan (BCP) is demonstrating which type of control?

- A. Corrective
- B. Preventive
- C. Detective
- D. Directive

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 337

Which of the following is necessary to determine what would constitute a disaster for an organization?

- A. Backup strategy analysis
- B. Threat probability analysis
- C. Risk analysis
- D. Recovery strategy analysis

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 338

Which of the following should be an information security manager's PRIMARY role when an organization initiates a data classification process?

- A. Assign the asset classification level.
- B. Define the classification structure to be implemented.
- C. Verify that assets have been appropriately classified.
- D. Apply security in accordance with specific classification.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 339

Which of the following would BEST protect against web-based cross-domain attacks?

- A. Network addressing scheme
- B. Database hardening
- C. Encryption controls
- D. Application controls

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 340

When using digital signatures, a sender transmits an encrypted message digest. This ensures that the:

- A. message is not intercepted during transmission
- B. message is not altered during transmission
- C. message sender obtains acknowledgement of delivery
- D. message remains confidential during transmission

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 341

An information security risk analysis BEST assists an organization in ensuring that:

- A. cost-effective decisions are made with regard to which assets need protection
- B. the organization implements appropriate security technologies
- C. the infrastructure has the appropriate level of access control
- D. an appropriate level of funding is applied to security processes

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 342

Which of the following would be the BEST way for an information security manager to justify ongoing annual maintenance fees associated with an intrusion prevention system (IPS)?

- A. Perform industry research annually and document the overall ranking of the IPS.
- B. Perform a penetration test to demonstrate the ability to protect.
- C. Establish and present appropriate metrics that track performance.
- D. Provide yearly competitive pricing to illustrate the value of the IPS.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 343

Reviewing which of the following would provide the GREATEST input to the asset classification process:

- A. Risk assessment
- B. Sensitivity of the data
- C. Replacement cost of the asset
- D. Compliance requirements

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 344

When building a corporate-wide business continuity plan, it is discovered there are two separate lines of business systems that could be impacted by the same threat. Which of the following is the BEST method to determine the priority of systems recovery in the event of a disaster?

- A. Reviewing the business plans of each department
- B. Evaluating the cost associated with each system's outage
- C. Reviewing each system's key performance indicators (KPIs)
- D. Comparing the recovery point objectives (RPOs)

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 345

Business applications should be selected for disaster recovery testing on the basis of:

- A. the results of contingency desktop checks
- B. the number of failure points that are being tested
- C. recovery time objectives (RTOs)
- D. criticality to the enterprise

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 346

When performing a data classification project, an information security manager should:

- A. assign information critically and sensitivity
- B. identify information owners
- C. identify information custodians
- D. assign information access privileges

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 347

A third-party service provider has proposed a data loss prevention (DLP) solution. Which of the following **MUST** be in place for this solution to be relevant to the organization?

- A. An adequate data testing environment
- B. Senior management support
- C. A business case
- D. A data classification

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 348

Which of the following is the **BEST** way to identify the potential impact of a successful attack on an organization's mission critical applications?

- A. Execute regular vulnerability scans
- B. Conduct penetration testing
- C. Perform an application vulnerability review
- D. Perform an independent code review

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 349

Which of the following needs be established **FIRST** in order to categorize data properly?

- A. A data protection policy
- B. A data classification framework
- C. A data asset inventory
- D. A data asset protection standard

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 350

Which of the following would provide the **BEST** justification for a new information security investment?

- A. Defined key performance indicators (KPIs)
- B. Projected reduction in risk

- C. Results of a comprehensive threat analysis
- D. Senior management involvement in project prioritization

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 351

Which of the following is MOST likely to prevent social engineering attacks?

- A. Security awareness program
- B. Employee background checks
- C. Implementing positive identification policies
- D. Enforcing stronger hiring policies

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 352

The recovery point objective (RPO) is required in which of the following?

- A. Information security plan
- B. Incident response plan
- C. Disaster recovery plan
- D. Business continuity plan

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 353

After assessing risk, the decision to treat the risk should be based PRIMARILY on:

- A. whether the level of risk exceeds risk appetite
- B. availability of financial resources
- C. whether the level of risk exceeds inherent risk
- D. the criticality of the risk

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 354

When preventive controls to appropriately mitigate risk are not feasible, which of the following is the MOST important action for the information security manager to perform?

- A. Identify unacceptable risk levels
- B. Manage the impact
- C. Evaluate potential threats
- D. Assess vulnerabilities

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 355

Which of the following is the PRIMARY purpose of data classification?

- A. To determine access rights to data
- B. To provide a basis for protecting data
- C. To select encryption technologies
- D. To ensure integrity of data

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 356

Before a failover test of a critical business application is performed, it is MOST important for the information security manager to:

- A. obtain a signed risk acceptance from the recovery team
- B. obtain senior management's approval
- C. inform the users that the test is taking place
- D. verify that the information assets have been classified properly

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 357

While conducting a test of a business continuity plan, which of the following is the MOST important consideration?

- A. The test simulates actual prime-time processing conditions.
- B. The test is scheduled to reduce operational impact.
- C. The test involves IT members in the test process.
- D. The test addresses the critical components.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 358

Which of the following would BEST support a business case to implement a data leakage prevention (DLP) solution?

- A. An unusual upward trend in outbound email volume
- B. Lack of visibility into previous data leakage incidents
- C. Industry benchmark of DLP investments
- D. A risk assessment on the threat of data leakage

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 359

Which of the following is the MOST important reason for performing vulnerability assessments periodically?

- A. Technology risks must be mitigated.
- B. Management requires regular reports.
- C. The environment changes constantly.
- D. The current threat levels are being assessed.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 360

A data leakage prevention (DLP) solution has identified that several employees are sending confidential company data to their personal email addresses in violation of company policy. The information security manager should FIRST:

- A. initiate an investigation to determine the full extent of noncompliance
- B. notify senior management that employees are breaching policy
- C. limit access to the Internet for employees involved
- D. contact the employees involved to retake security awareness training

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 361

Determining the risk for a particular threat/vulnerability pair before controls are applied can be expressed as:

- A. the likelihood of a given threat attempting to exploit a vulnerability
- B. a function of the cost and effectiveness of controls over a vulnerability
- C. the magnitude of the impact should a threat exploit a vulnerability
- D. a function of the likelihood and impact, should a threat exploit a vulnerability

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 362

Which of the following methods of providing telecommunications continuity involves the use of an alternative media?

- A. Alternative routing
- B. Diverse routing
- C. Long haul network diversity
- D. Last mile circuit protection

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Alternative routing is a method of routing information via an alternate medium such as copper cable or fiber optics. This involves use of different networks, circuits or end points should the normal network be unavailable. Diverse routing routes traffic through split cable facilities or duplicate cable facilities. This can be accomplished with different and/or duplicate cable sheaths. If different cable sheaths are used, the cable may be in the same conduit and therefore subject to the same interruptions as the cable it is backing up. The communication service subscriber can duplicate the facilities by having alternate routes, although the entrance to and from the customer premises may be in the same conduit. The subscriber can obtain diverse routing and alternate routing from the local carrier, including dual entrance facilities. This type of access is time-consuming and costly. Long haul network diversity is a diverse long-distance network utilizing T1 circuits among the major long-distance carriers. It ensures long-distance access should any one carrier experience a network failure. Last mile circuit protection is a redundant combination of local carrier T1s microwave and/or coaxial cable access to the local communications loop. This enables the facility to have access during a local carrier communication disaster. Alternate local carrier routing is also utilized. Reference: Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, chapter 5: Disaster Recovery and Business Continuity (page 259).

QUESTION 363

Which of the following should be the FIRST step to help ensure the necessary regulatory requirements are addressed in an organization's cross-border data protection policy?

- A. Conduct a risk assessment
- B. Perform a gap analysis
- C. Conduct stakeholder interviews
- D. Perform a business impact analysis (BIA)

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 364

To protect information assets, which of the following should be done FIRST?

- A. Restrict access to data
- B. Encrypt data
- C. Classify data
- D. Back up data

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 365

Which of the following should an IS auditor recommend be done FIRST upon learning that new data protection legislation may affect the organization?

- A. Implement data protection best practices
- B. Implement a new security baseline for achieving compliance
- C. Restrict system access for noncompliant business processes
- D. Perform a gap analysis of data protection practices

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 366

Data confidentiality is a requirement for an organization's new web service. Which of the following would provide the BEST protection?

- A. Telnet
- B. Secure Sockets Layer (SSL)
- C. Transport Layer Security (TLS)
- D. Secure File Transfer Protocol (SFTP)

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 367

Which of the following methods would BEST help detect unauthorized disclosure of confidential documents sent over corporate email?

- A. Installing firewalls on the corporate network
- B. Requiring all users to encrypt documents before sending
- C. Monitoring all emails based on pre-defined criteria
- D. Reporting all outgoing emails that are marked as confidential

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 368

An employee has accidentally posted confidential data to the company's social media page. Which of the following is the BEST control to prevent this from recurring?

- A. Require all updates to be made by the marketing director
- B. Implement a moderator approval process
- C. Perform periodic audits of social media updates
- D. Establish two-factor access control for social media accounts

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 369

Which of the following is the BEST method to prevent wire transfer fraud by bank employees?

- A. Re-keying of wire dollar amounts
- B. Independent reconciliation
- C. Two-factor authentication control
- D. System-enforced dual control

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 370

The BEST way to assure an organization's board of directors that IT strategies support business objectives is to:

- A. provide regular assessments of emerging technologies
- B. identify and report on the achievement of critical success factors (CSFs)
- C. confirm that IT strategies have been fully documented and disseminated
- D. ensure that senior business managers review IT budgets

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 371

Which of the following is the BEST preventative control to protect the confidentiality of data on a corporate smartphone in the event it is lost?

- A. Encryption of the data stored on the device
- B. Biometric authentication for the device
- C. Password for device authentication
- D. Remote data wipe program

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 372

The FIRST step in establishing a firewall security policy is to determine the:

- A. necessary logical access rights.
- B. expected data throughput.
- C. business requirements.
- D. existing firewall configuration.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 373

Which of the following is the MOST effective way to reduce risk to an organization from widespread use of web-based communication technologies?

- A. Publish an enterprise-wide policy outlining acceptance use of web-based communication technologies.
- B. Incorporate risk awareness training for web-based communications into the IT security program.
- C. Monitor staff usage of web-based communication and notify the IT security department of violations.
- D. Block access from user devices to unauthorized pages that allow web-based communication.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 374

Which of the following will enable a customer to authenticate an online Internet vendor?

- A. Vendor signs a reply using a hash function and the customer's public key.
- B. Customer encrypts an order using the vendor's public key.

- C. Customer verifies the vendor's certificate with a certificate authority (CA).
- D. Vendor decrypts incoming orders using its own private key.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 375

Which of the following is MOST likely to enable a hacker to successfully penetrate a system?

- A. Lack of virus protection
- B. Unpatched software
- C. Decentralized dialup access
- D. Lack of DoS protection

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 376

An IS auditor is reviewing security controls related to collaboration tools for a business unit responsible for intellectual property and patents. Which of the following observations should be of MOST concern to the auditor?

- A. Training was not provided to the department that handles intellectual property and patents.
- B. Logging and monitoring for content filtering is not enabled.
- C. The collaboration tool is hosted and can only be accessed via an Internet browser.
- D. Employees can share files with users outside the company through collaboration tools.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 377

A stockbroker accepts orders over the Internet. Which of the following is the MOST appropriate control to ensure confidentiality of the orders?

- A. Virtual private network (VPN)
- B. Public key encryption
- C. Data Encryption Standard (DES)
- D. Digital signature

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 378

Which of the following is MOST likely to be prevented by a firewall connected to the Internet?

- A. Dial-in penetration attacks
- B. Disclosure of public key infrastructure (PKI) keys
- C. Alteration of email message content
- D. External spoofing of internal addresses

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 379

To confirm integrity for a hashed message, the receiver should use:

- A. a different hashing algorithm from the sender's to create a numerical representation of the file.
- B. a different hashing algorithm from the sender's to create a binary image of the file.
- C. the same hashing algorithm as the sender's to create a binary image of the file.
- D. the same hashing algorithm as the sender's to create a numerical representation of the file.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 380

The use of the Transport Layer Security (TLS) protocol enables the client in a network to be:

- A. provided with a digital certificate.
- B. identified by a password.
- C. registered by the server.
- D. assured of the server's identity.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 381

Which of the following is the GREATEST advantage of application penetration testing over vulnerability scanning?

- A. Penetration testing does not require a special skill set to be executed.
- B. Penetration testing provides a more accurate picture of gaps in application controls.
- C. Penetration testing can be conducted in a relatively short time period.
- D. Penetration testing creates relatively smaller risks to application availability and integrity.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 382

A bank is relocating its servers to a vendor that provides data center hosting services to multiple clients. Which of the following controls would restrict other clients from physical access to the bank's servers?

- A. Closed-circuit television cameras
- B. Locking server cages
- C. Biometric access at all data center entrances
- D. 24-hour security guards

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 383

Which of the following is the BEST approach to identify whether a vulnerability is actively being exploited?

- A. Implement key performance indicators (KPIs).
- B. Conduct a penetration test.
- C. Review service desk reports.
- D. Perform log analysis.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 384

Which of the following validation techniques would BEST prevent duplicate electronic vouchers?

- A. Cyclic redundancy check
- B. Edit check
- C. Reasonableness check
- D. Sequence check

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 385

On a daily basis, an in-house development team moves duplicate copies of production data containing personally identifiable information (PII) to the test environment. Which of the following is the BEST way to mitigate the privacy risk involved?

- A. Require data owners to sign off on production data.
- B. Encrypt the data file.
- C. Obtain customer opt-in acceptances.
- D. Sanitize the data in the test environment.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 386

Which of the following is the BEST indicator of the effectiveness of signature-based intrusion detection systems (IDSs)?

- A. An increase in the number of identified false positives
- B. An increase in the number of unfamiliar sources of intruders
- C. An increase in the number of detected incidents not previously identified
- D. An increase in the number of internally reported critical incidents

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 387

Which of the following would BEST detect logic bombs in the new programs?

- A. Final acceptance testing by users
- B. Parallel/pilot testing
- C. Regression testing
- D. Independent program review

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 388

Which of the following is the MOST effective way to prevent unauthorized changes from being moved into production?

- A. Conduct periodic review of change tickets to ensure all change documentation is attached.
- B. Enforce segregation of duties between developers and migrators.
- C. Perform thorough testing of changes in the test environment.
- D. Require approval of changes by the appropriate business process owners.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 389

The FIRST course of action an investigator should take when a computer is being attacked is to:

- A. terminate all active processes.
- B. copy the contents of the hard drive.
- C. disconnect it from the network.
- D. disconnect the power source.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 390

In which phase of penetration testing would host detection and domain name system (DNS) interrogation be performed?

- A. Reporting
- B. Attacks
- C. Discovery
- D. Planning

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 391

Which of the following would be the MOST likely reason for an intrusion prevention system (IPS) being unable to block an ongoing web attack?

- A. The firewall is not configured properly.
- B. The network design contains flaws.
- C. Monitoring personnel are not proactive.
- D. Signatures are outdated.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 392

Which of the following will BEST protect the confidentiality of data stored on the hard drive of a laptop computer?

- A. Encryption of the data
- B. A boot password
- C. Physical locks and alarms
- D. Biometric access control

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 393

Due to the increasing size of a database, user access times and daily backups continue to increase. Which of the following is the BEST way to address this situation?

- A. Data modeling
- B. Data visualization
- C. Data mining
- D. Data purging

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 394

Documentation of workaround processes to keep a business function operational during recovery of IT systems is a core part of a:

- A. business impact analysis (BIA).
- B. threat and risk assessment.
- C. business continuity plan (BCP).
- D. disaster recovery plan (DRP).

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 395

Which of the following protects against the impact of temporary and rapid decreases or increases in electricity?

- A. Redundant power supply
- B. Emergency power-off switch
- C. Stand-by generator
- D. Uninterruptible power supply (UPS)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 396

An organization using instant messaging to communicate with customers can prevent legitimate customers from being impersonated by:

- A. using call monitoring.
- B. using firewalls to limit network traffic to authorized ports.
- C. logging conversations.
- D. authenticating users before conversations are initiated.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 397

During a disaster recovery audit, an IS auditor finds that a business impact analysis (BIA) has not been performed. The auditor should FIRST:

- A. perform a business impact analysis (BIA).
- B. issue an intermediate report to management.
- C. evaluate the impact on current disaster recovery capability.
- D. conduct additional compliance testing.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 398

During the testing of the business continuity plan (BCP), which of the following methods of results analysis provides the BEST assurance that the plan is workable?

- A. Measurement of accuracy
- B. Elapsed time for completion of critical tasks
- C. Quantitatively measuring the results of the test
- D. Evaluation of the observed test results

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is important to have ways to measure the success of the plan and tests against the stated objectives. Therefore, results must be quantitatively gauged as opposed to an evaluation based only on observation. Quantitatively measuring the results of the test involves a generic statement measuring all the activities

performed during BCP, which gives the best assurance of an effective plan. Although choices A and B are also quantitative, they relate to specific areas, or an analysis of results from one viewpoint, namely the accuracy of the results and the elapsed time.

Reference: Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, Chapter 5: Disaster Recovery and Business Continuity (page 269).

QUESTION 399

Which of the following statements regarding an off-site information processing facility is TRUE?

- A. It should have the same amount of physical access restrictions as the primary processing site.
- B. It should be located in proximity to the originating site so that it can quickly be made operational.
- C. It should be easily identified from the outside so in the event of an emergency it can be easily found.
- D. Need not have the same level of environmental monitoring as the originating site since this would be cost prohibitive.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is very important that the offsite has the same restrictions in order to avoid misuse.

The following answers are incorrect because:

It should be located in proximity to the originating site so that it can quickly be made operational is incorrect as the offsite is also subject to the same disaster as of the primary site.

It should be easily identified from the outside so in the event of an emergency it can be easily found is also incorrect as it should not be easily identified to prevent intentional sabotage.

Need not have the same level of environmental monitoring as the originating site since this would be cost prohibitive is also incorrect as it should be like its primary site.

Reference: Information Systems Audit and Control Association, Certified Information Systems Auditor 2002 review manual, chapter 5: Disaster Recovery and Business Continuity (page 265).

QUESTION 400

Business Continuity Planning (BCP) is not defined as a preparation that facilitates:

- A. the rapid recovery of mission-critical business operations
- B. the continuation of critical business functions
- C. the monitoring of threat activity for adjustment of technical controls
- D. the reduction of the impact of a disaster

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The following answers are incorrect:

All of the other choices are facilitated by a BCP:

the continuation of critical business functions

the rapid recovery of mission-critical business operations

the reduction of the impact of a disaster

QUESTION 401

As described at security policy, the CSO implemented an e-mail package solution that allows for ensuring integrity of messages sent using SMIME. Which of the options below BEST describes how it implements the environment to suite policy's requirement?

- A. Implementing PGP and allowing for recipient to receive the private key used to sign e-mail message.
- B. Implementing RSA standard for messages envelope and instructing users to sign all messages using their private key from their PKI digital certificate.
- C. Implementing RSA standard for messages envelope and instructing users to sign all messages using their public key from their PKI digital certificate.
- D. Implementing MIME solutions and providing a footer within each message sent, referencing to policy constraints related to e-mail usage.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

RSA e-mail standard stands for SMIME envelope. Using tm's private key to sign messages, users will ensure recipients of message integrity by using sender's public key for hash decryption and content comparison.

Exam candidates should be aware of e-mail solutions and technologies that addresses confidentiality, integrity and non-repudiation.

The following answers are incorrect:

Implementing PGP and allowing for recipient to receive the private key used to sign e-mail message.

Implementing RSA standard for messages envelope and instructing users to sign all messages using their public key from the PKI digital certificate.

Implementing MIME solutions and providing a footer within each message sent, referencing to policy constraints related to e-mail usage.
CISA Review Manual 2010 - Chapter 5 - 5.4.5-Encryption - Digital Envelope

QUESTION 402

How often should a Business Continuity Plan be reviewed?

- A. At least once a month
- B. At least every six months
- C. At least once a year
- D. At least Quarterly

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

As stated in SP 800-34 Rev. 1:

To be effective, the plan must be maintained in a ready state that accurately reflects system requirements, procedures, organizational structure, and policies. During the Operation/Maintenance phase of the SDLC, information systems undergo frequent changes because of shifting business needs, technology upgrades, or new internal or external policies.

As a general rule, the plan should be reviewed for accuracy and completeness at an organization-defined frequency (at least once a year for the purpose of the exam) or whenever significant changes occur to any element of the plan. Certain elements, such as contact lists, will require more frequent reviews. Remember, there could be two good answers as specified above. Either once a year or whenever significant changes occur to the plan. You will of course get only one of the two presented within your exam.

NIST SP 800-34 Revision 1

QUESTION 403

Which of the following attack involves slicing small amount of money from a computerize transaction or account?

- A. Eavesdropping
- B. Traffic Analysis
- C. Salami
- D. Masquerading

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Salami slicing or Salami attack refers to a series of many small actions, often performed by clandestine means, that as an accumulated whole produces a much larger action or result that would be difficult or unlawful to perform all at once. The term is typically used pejoratively. Although salami slicing is often used to carry out illegal activities, it is only a strategy for gaining an advantage over time by accumulating it in small increments, so it can be used in perfectly legal ways as well.

An example of salami slicing, also known as penny shaving, is the fraudulent practice of stealing money repeatedly in extremely small quantities, usually by taking advantage of rounding to the nearest cent (or other monetary unit) in financial transactions. It would be done by always rounding down, and putting the fractions of a cent into another account. The idea is to make the change small enough that any single transaction will go undetected.

In information security, a salami attack is a series of minor attacks that together results in a larger attack. Computers are ideally suited to automating this type of attack.

The following answers are incorrect:

Eavesdropping is the act of secretly listening to the private conversation of others without their consent, as defined by Black's Law Dictionary. This is commonly thought to be unethical and there is an old adage that "eavesdroppers seldom hear anything good of themselves...eavesdroppers always try to listen to matters that concern them."

Traffic analysis is the process of intercepting and examining messages in order to deduce information from patterns in communication. It can be performed even when the messages are encrypted and cannot be decrypted. In general, the greater the number of messages observed, or even intercepted and stored, the more can be inferred from the traffic. Traffic analysis can be performed in the context of military intelligence, counter-intelligence, or pattern-of-life analysis, and is a concern in computer security.

Masquerading A masquerade attack is an attack that uses a fake identity, such as a network identity, to gain unauthorized access to personal computer information through legitimate access identification. If an authorization process is not fully protected, it can become extremely vulnerable to a masquerade attack. Masquerade attacks can be perpetrated using stolen passwords and logons, by locating gaps in programs, or by finding a way around the authentication process. The attack can be triggered either by someone within the organization or by an outsider if the organization is connected to a public network. The amount of access masquerade attackers get depends on the level of authorization they've managed to attain. As such, masquerade attackers can have a full smorgasbord of cybercrime opportunities if they've gained the highest access authority to a business organization. Personal attacks, although less common, can also be harmful. <http://searchfinancialsecurity.techtarget.com/definition/eavesdropping> http://en.wikipedia.org/wiki/Salami_slicing <http://en.wikipedia.org/wiki/Eavesdropping> http://en.wikipedia.org/wiki/Traffic_analysis <http://www.techopedia.com/definition/4020/masquerade-attack>

QUESTION 404

Which of the following attack best describe "Computer is the target of a crime" and "Computer is the tool of a crime"?

- A. Denial of Service (DoS) and Installing Key loggers
- B. War Driving and War Chalking
- C. Piggybacking and Race Condition
- D. Traffic analysis and Eavesdropping

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In computing, a denial-of-service (DoS) or distributed denial-of-service (DDoS) attack is an attempt to make a machine or network resource unavailable to its intended users. Although the means to carry out, motives for, and targets of a DoS attack may vary, it generally consists of efforts to temporarily or indefinitely interrupt or suspend services of a host connected to the Internet. As clarification, DDoS (Distributed Denial of Service) attacks are sent by two or more persons, or bots. (See botnet) DoS (Denial of Service) attacks are sent by one person or system.

Keystroke logging, often referred to as key logging or keyboard capturing, is the action of recording (or logging) the keys struck on a keyboard, typically in a covert manner so that the person using the keyboard is unaware that their actions are being monitored. It also has very legitimate uses in studies of human-computer interaction. There are numerous key logging methods, ranging from hardware and software-based approaches

to acoustic analysis.

There are four types of a computer crimes:

1. Computer is the target of a crime Perpetrator uses another computer to launch an attack. In this attack the target is a specific identified computer. Ex. Denial of Service (DoS), hacking
2. Computer is the Subject of a crime In this attack perpetrator uses computer to commit crime and the target is another computer. In this attack, target may or

may not be defined. Perpetrator launches attack with no specific target in mind. Ex. Distributed DoS, Malware

3. Computer is the tool of a crime Perpetrator uses computer to commit crime but the target is not a computer. Target is the data or information stored on a computer. Ex. Fraud, unauthorized access, phishing, installing key logger

4. Computer Symbolizes Crime Perpetrator lures the user of a computer to get confidential information. Target is user of computer. Ex. Social engineering methods like Phishing, Fake website, Scam Mails, etc

The following answers are incorrect:

Eavesdropping is the act of secretly listening to the private conversation of others without their consent, as defined by Black's Law Dictionary. This is commonly thought to be unethical and there is an old adage that "eavesdroppers seldom hear anything good of themselves...eavesdroppers always try to listen to matters that concern them."

Traffic analysis is the process of intercepting and examining messages in order to deduce information from patterns in communication. It can be performed even when the messages are encrypted and cannot be decrypted. In general, the greater the number of messages observed, or even intercepted and stored, the more can be inferred from the traffic. Traffic analysis can be performed in the context of military intelligence, counter-intelligence, or pattern-of-life analysis, and is a concern in computer security.

Masquerading A masquerade attack is an attack that uses a fake identity, such as a network identity, to gain unauthorized access to personal computer information through legitimate access identification. If an authorization process is not fully protected, it can become extremely vulnerable to a masquerade attack. Masquerade attacks can be perpetrated using stolen passwords and logons, by locating gaps in programs, or by finding a way around the authentication process. The attack can be triggered either by someone within the organization or by an outsider if the organization is connected to a public network. The amount of access masquerade attackers get depends on the level of authorization they've managed to attain. As such, masquerade attackers can have a full smorgasbord of cybercrime opportunities if they've gained the highest access authority to a business organization. Personal attacks, although less common, can also be harmful. CISA review Manual 2014. Page number 321

http://en.wikipedia.org/wiki/Denial-of-service_attack

<http://en.wikipedia.org/wiki/Eavesdropping>

http://en.wikipedia.org/wiki/Traffic_analysis

<http://www.techopedia.com/definition/4020/masquerade-attack>

QUESTION 405

Which of the following is NOT a disadvantage of Single Sign On (SSO)?

- A. Support for all major operating system environment is difficult
- B. The cost associated with SSO development can be significant
- C. SSO could be single point of failure and total compromise of an organization asset
- D. SSO improves an administrator's ability to manage user's account and authorization to all associated system

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Single sign-on (SSO) is a Session/user authentication process that permits a user to enter one name and password in order to access multiple applications. The process authenticates the user for all the applications they have been given rights to and eliminates further prompts when they switch applications during a particular session.

SSO Advantages include

Multiple passwords are no longer required

It improves an administrator's ability to manage user's accounts and authorization to all associated systems It reduces administrative overhead in resetting forgotten password over multiple platforms and applications It reduces time taken by users to logon into multiple application and platform

SSO Disadvantages include

Support for all major operating system is difficult

The cost associated with SSO development can be significant when considering the nature and extent of interface development and maintenance that may be necessary

The centralized nature of SSO presents the possibility of a single point of failure and total compromise of an organization's information asset.

CISA review manual 2014 Page number 332

QUESTION 406

An IS auditor is reviewing the remote access methods of a company used to access system remotely. Which of the following is LEAST preferred remote access method from a security and control point of view?

- A. RADIUS
- B. TACACS
- C. DIAL-UP
- D. DIAMETER

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Dial-up connectivity not based on centralized control and least preferred from security and control standpoint.

Remote access user can connect remotely to their organization's networks with the same level of functionality as if they would access from within their office.

In connecting to an organization's network, a common method is to use dial-up lines. Access is granted through the organization's network access server (NAS) working in concert with an organization network firewall and router. The NAS handle user authentication, access control and accounting while maintaining connectivity. The most common protocol for doing this is the Remote Access Dial-In User Service (RADIUS) and Terminal Access Controller Access Controller System (TACACS).

Remote access Controls include:

Policy and standard

Proper authorization

Identification and authentication mechanism

Encryption tool and technique such as use of VPN

System and network management

QUESTION 407

There are many types of audit logs analysis tools available in the market. Which of the following audit logs analysis tools will look for anomalies in user or system behavior?

- A. Attack Signature detection tool
- B. Variance detection tool
- C. Audit Reduction tool
- D. Heuristic detection tool

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Trend/Variance Detection tool are used to look for anomalies in user or system behavior. For example, if a user typically logs in at 9:00 am, but one day suddenly access the system at 4:30 am, this may indicate a security problem that may need to be investigated.

Other types of audit trail analysis tools should also be known for your CISA exam

The following were incorrect answers:

Audit Reduction tool - They are preprocessor designed to reduce the volume of audit records to facilitate manual review. Before a security review, these tool can remove many audit records known to have little security significance.

Attack-signature detection tool - They look for an attack signature, which is a specific sequence of events indicative of an unauthorized access attempt. A simple example would be repeated failed logon attempts. Heuristic detection tool - Heuristic analysis is an expert based analysis that determines the susceptibility of a system towards particular threat/risk using various decision rules or weighing methods. MultiCriteria analysis (MCA) is one of the means of weighing. This method differs with statistical analysis, which bases itself on the available data/statistics.

CISA review manual 2014 Page number 336

and

http://en.wikipedia.org/wiki/Heuristic_analysis

QUESTION 408

As an IS auditor, it is very important to make sure all storage media are well protected. Which of the following is the LEAST important factor for protecting CDs and DVDs?

- A. Handle by edges or by the hole in the middle
- B. Store in anti-static bag
- C. Avoid long term exposure to bright light
- D. Store in a hard jewel case, not in soft sleeves

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

CDs and DVDs are least affected by static current so it is not as important to store them into anti-static bags.

CDs and DVDs Storage protection recommendations:

Handle by edges or by hole in the middle

Be careful not to bend the CD or DVD

Avoid long term exposure to bright light

Store in a hard jewel case, not in soft sleeves

Also, you should know the media storage precautions listed below in preparation for the CISA exam:

USB and portable hard drive

Avoid high temperature, humidity extremes and strong magnetic field

Tape Cartridges

Store Cartridges vertically

Store cartridges in a protective container for transport

Write-protect cartridges immediately

Hard Drive

Store hard drives in anti-static bags, and be sure that person removing them from bag is static free If the original box and padding for the hard drive is available, use it for shipping If the hard drive has been in a cold environment, bring it to room temperature prior to installing and using it Reference used - CISA review manual 2014. Page number 338

QUESTION 409

As an auditor it is very important to ensure confidentiality, integrity, authenticity and availability are implemented appropriately in an information system. Which of the following definitions incorrectly describes these parameters?

1. Authenticity A third party must be able to verify that the content of a message has been sent by a specific entity and nobody else.
 2. Non-repudiation The origin or the receipt of a specific message must be verifiable by a third party. A person cannot deny having sent a message if the message is signed by the originator.
 3. Accountability The action of an entity must be uniquely traceable to different entities
 4. Availability The IT resource must be available on a timely basis to meet mission requirements or to avoid substantial losses.
- A. All of the options presented
 - B. None of the options presented
 - C. Options number 1 and 2
 - D. Option number 3

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is important to read carefully the question. The word "incorrectly" was the key word. You had to find which one of the definitions presented is incorrect. The definition of Accountability was NOT properly described. Below you have the proper definition.

The correct definitions are as follows

Authenticity A third party must be able to verify that the content of a message is from a specific entity and nobody else.

Non-repudiation The origin or the receipt of a specific message must be verifiable by a third party. A person cannot deny having sent a message if the message is signed by the originator.

Accountability The action of an entity must be uniquely traceable to that entity
Network availability The IT resource must be available on a timely basis to meet mission requirements or to avoid substantial losses.
CISA review manual 2014 Page number 34

QUESTION 410

Which of the following statement correctly describes difference between packet filtering firewall and stateful inspection firewall?

- A. Packet filtering firewall do not maintain client session whereas Stateful firewall maintains client session.
- B. Packet filtering firewall and Stateful firewall both maintain session of client.
- C. Packet filtering firewall is a second generation firewall whereas Stateful is a first generation of firewall.
- D. Packet filtering firewall and Stateful firewall do not maintain any session of client.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Packet Filtering Firewall

Also Known as First Generation Firewall

Do not maintain client session

The advantage of this type of firewall are simplicity and generally stable performance since the filtering rules are performed at the network layer.

Its simplicity is also disadvantage, because it is vulnerable to attack from improperly configured filters and attack tunneled over permitted services. Some of the more common attack on packet filtering are IP Spoofing, Source Routing specification, Miniature fragment attack.

Stateful Inspection Firewall

A stateful inspection firewall keep track of the destination IP address of each packet that leaves the

organization's internal network.

The session tracking is done by mapping the source IP address of incoming packet with the list of destination IP addresses that is maintained and updated

This approach prevent any attack initiated and originated by outsider. The disadvantage includes stateful inspection firewall can be relatively complex to administer as compare to other firewall.

The following were incorrect answers:

All other choices presented were incorrect answers because they all had the proper definition.

CISA review manual 2014 Page number 345 and 346

QUESTION 411

There are many firewall implementations provided by firewall manufacturers. Which of the following implementation utilize two packet filtering routers and a bastion host? This approach creates the most secure firewall system since it supports network and application level security while defining a separate DMZ.

- A. Dual Homed firewall
- B. Screened subnet firewall
- C. Screened host firewall
- D. Anomaly based firewall

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In network security, a screened subnet firewall is a variation of the dual-homed gateway and screened host firewall. It can be used to separate components of the firewall onto separate systems, thereby achieving greater throughput and flexibility, although at some cost to simplicity. As each component system of the screened subnet firewall needs to implement only a specific task, each system is less complex to configure. A screened subnet firewall is often used to establish a demilitarized zone (DMZ).

Below are few examples of Firewall implementations:

Screened host Firewall

Utilizing a packet filtering router and a bastion host, this approach implements a basic network layer security and application server security.

An intruder in this configuration has to penetrate two separate systems before the security of the private network can be compromised

This firewall system is configured with the bastion host connected to the private network with a packet filtering router between internet and the bastion host

Dual-homed Firewall

A firewall system that has two or more network interface, each of which is connected to a different network In a firewall configuration, a dual homed firewall system usually acts to block or filter some or all of the traffic trying to pass between the network

A dual-homed firewall system is more restrictive form of screened-host firewall system

Demilitarize Zone (DMZ) or screened-subnet firewall

Utilizing two packet filtering routers and a bastion host

This approach creates the most secure firewall system since it supports network and application level security

while defining a separate DMZ network
Typically, DMZs are configured to limit access from the internet and organization's private network.

The following were incorrect answers:

The other types of firewall mentioned in the option do not utilize two packet filtering routers and a bastion host.
CISA review manual 2014 Page number 346

QUESTION 412

Which of the following type of IDS has self-learning functionality and over a period of time will learn what is the expected behavior of a system?

- A. Signature Based IDS
- B. Host Based IDS
- C. Neural Network based IDS
- D. Statistical based IDS

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Neural Network based IDS monitors the general patterns of activity and traffic on the network, and create a database of normal activities within the system. This is similar to statistical model but with added self-learning functionality.

Also, you should know below categories and types of IDS for CISA exam:

An IDS works in conjunction with routers and firewall by monitoring network usage anomalies.

Broad category of IDS includes:

Network based IDS
Host based IDS

Network Based IDS

They identify attack within the monitored network and issue a warning to the operator. If a network based IDS is placed between the Internet and the firewall, it will detect all the attack attempts whether or not they enter the firewall

Host Based IDS

They are configured for a specific environment and will monitor various internal resources of the operating system to warn of a possible attack.
They can detect the modification of executable programs, detect the detection of files and issue a warning when an attempt is made to use a privilege account.

Types of IDS includes

Signature Based IDS These IDS system protect against detected intrusion patterns. The intrusive pattern they can identify are stored in the form of signature.
Statistical Based IDS This system needs a comprehensive definition of the known and expected behavior of system
Neural Network An IDS with this feature monitors the general patterns of activity and traffic on the network,

and create a database. This is similar to statistical model but with added self-learning functionality

The following were incorrect answers:

The other types of IDS mentioned in the options do not monitor general patterns of activities and contains self- learning functionalities.
CISA review manual 2014 Page number 346 and 347

QUESTION 413

Which of the following type of an IDS resides on important systems like database, critical servers and monitors various internal resources of an operating system?

- A. Signature based IDS
- B. Host based IDS
- C. Network based IDS
- D. Statistical based IDS

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Host Based IDS resides on important systems like database, critical servers and monitors various internal resources of an operating system.

Also, you should know below mentioned categories and types of IDS for CISA exam

An IDS works in conjunction with routers and firewall by monitoring network usage anomalies.
Broad categories of IDS include:

1. Network Based IDS
2. Host Based IDS

Network Based IDS

They identify attack within the monitored network and issue a warning to the operator. If a network based IDS is placed between the Internet and the firewall, it will detect all the attack attempts whether or not they enter the firewall
Network Based IDS are blinded when dealing with encrypted traffic

Host Based IDS

They are configured for a specific environment and will monitor various internal resources of the operating system to warn of a possible attack.
They can detect the modification of executable programs, detect the detection of files and issue a warning when an attempt is made to use a privilege account.
They can monitor traffic after it is decrypted and they supplement the Network Based IDS.

Types of IDS includes:

Statistical Based IDS This system needs a comprehensive definition of the known and expected behavior of system

Neural Network An IDS with this feature monitors the general patterns of activity and traffic on the network, and create a database. This is similar to statistical model but with added self-learning functionality.

Signature Based IDS These IDS system protect against detected intrusion patterns. The intrusive pattern they can identify are stored in the form of signature.

The following were incorrect answers:

The other types of IDS mentioned in the options do not resides on important systems like database and critical servers
CISA review manual 2014 Page number 346 and 347

QUESTION 414

There are many known weaknesses within an Intrusion Detection System (IDS). Which of the following is NOT a limitation of an IDS?

- A. Weakness in the identification and authentication scheme.
- B. Application level vulnerability.
- C. Backdoor into application
- D. Detect zero day attack.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Detecting zero day attack is an advantage of IDS system making use of behavior or heuristic detection.

It is important to read carefully the question. The word "NOT" was the key word.

Intrusion Detection System are somewhat limited in scope, they do not address the following:

Weakness in the policy definition

Application-level vulnerability

Backdoor within application

Weakness in identification and authentication schemes

Also, you should know the information below for your CISA exam:

An IDS works in conjunction with routers and firewall by monitoring network usage anomalies.

Broad category of IDS includes:

1. Network Based IDS
2. Host Based IDS

Network Based IDS

They identify attack within the monitored network and issue a warning to the operator. If a network based IDS is placed between the Internet and the firewall, it will detect all the attack attempts whether or not they enter the firewall

Network Based IDS are blinded when dealing with encrypted traffic

Host Based IDS

They are configured for a specific environment and will monitor various internal resources of the operating system to warn of a possible attack.

They can detect the modification of executable programs, detect the detection of files and issue a warning

when an attempt is made to use a privilege account.

They can monitor traffic after it is decrypted and they supplement the Network Based IDS.

Types of IDS includes:

Statistical Based IDS This system needs a comprehensive definition of the known and expected behavior of system

Neural Network An IDS with this feature monitors the general patterns of activity and traffic on the network, and create a database. This is similar to statistical model but with added self-learning functionality.

Signature Based IDS These IDS system protect against detected intrusion patterns. The intrusive pattern they can identify are stored in the form of signature.

The following were incorrect answers:

The other options mentioned are all limitations of an IDS.

CISA review manual 2014 Page number 346 and 347

QUESTION 415

Which of the following is a software application that pretend to be a server on the Internet and is not set up purposely to actively protect against break-ins?

- A. Bastion host
- B. Honey pot
- C. Dual Homed
- D. Demilitarize Zone (DMZ)

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A Honey pot is a software application or system that pretends to be a normal server on the internet and it is not set up actively protect against all break-ins. In purpose, some of the updates, patches, or upgrades are missing.

You then monitor the honey pot to learn from the offensive side.

There are two types of honey pot:

High-interaction Honey pots Essentially gives hacker a real environment to attack. High-interaction honey pots imitate the activities of the production systems that

host a variety of services and, therefore, an attacker may be allowed a lot of services to waste his time. According to recent research into high-interaction honey pot technology, by employing virtual machines, multiple honey pots can be hosted on a single physical machine. Therefore, even if the honey pot is compromised, it can be restored more quickly. In general, high-interaction honey pots provide more security by being difficult to detect, but they are highly expensive to maintain. If virtual machines are not available, one honey pot must be maintained for each physical computer, which can be exorbitantly expensive. Example: Honey net.

Low interaction Emulate production environment and therefore, provide more limited information. Low- interaction honey pots simulate only the services frequently requested by attackers. Since they consume relatively few resources, multiple virtual machines can easily be hosted on one physical system, the virtual systems have a short response time, and less code is required, reducing the complexity of the virtual system's security. Example: Honeyed.

The following were incorrect answers:

Bastion host - On the Internet, a bastion host is the only host computer that a company allows to be addressed directly from the public network and that is designed to screen the rest of its network from security exposure. DMZ or Demilitarize Zone In computer networks, a DMZ (demilitarized zone) is a computer host or small network inserted as a "neutral zone" between a company's private network and the outside public network. It prevents outside users from getting direct access to a server that has company data. Dual Homed - Dual- homed or dual-homing can refer to either an Ethernet device that has more than one network interface, for redundancy purposes, or in firewall technology, dual-homed is one of the firewall architectures for implementing preventive security.

Dual-Homed - An example of dual-homed devices are enthusiast computing motherboards that incorporate dual Ethernet network interface cards or a firewall with two network interface cards. One facing the external network and one facing the internal network.
CISA review manual 2014 Page number 348

<http://searchsecurity.techtarget.com/definition/bastion-host> <http://searchsecurity.techtarget.com/definition/DMZ> http://en.wikipedia.org/wiki/Honeypot_%28computing%29
<http://en.wikipedia.org/wiki/Dual-homed>

QUESTION 416

Which of the following type of honey pot essentially gives a hacker a real environment to attack?

- A. High-interaction
- B. Low-interaction
- C. Med-interaction
- D. None of the choices

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

High-interaction type of honey pot essentially gives an attacker a real environment to attack.

Also, you should know below information about honey pot for CISA exam:

A Honey pot is a software application that pretends to be an unfortunate server on the internet and is not set up actively protect against break-ins.

There are two types of honey pot:

High-interaction Honey pots Essentially gives hacker a real environment to attack. High-interaction honey pots imitate the activities of the production systems that host a variety of services and, therefore, an attacker may be allowed a lot of services to waste his time. According to recent research into high-interaction honey pot technology, by employing virtual machines, multiple honey pots can be hosted on a single physical machine. Therefore, even if the honey pot is compromised, it can be restored more quickly. In general, high-interaction honey pots provide more security by being difficult to detect, but they are highly expensive to maintain. If virtual machines are not available, one honey pot must be maintained for each physical computer, which can be exorbitantly expensive. Example: Honey net.
Low interaction Emulate production environment and therefore, provide more limited information. Low- interaction honey pots simulate only the services frequently requested by attackers. Since they consume relatively few resources, multiple virtual machines can easily be hosted on one physical system, the virtual

systems have a short response time, and less code is required, reducing the complexity of the virtual system's security. Example: Honeyed.

The following were incorrect answers:

Med-interaction Not a real type of honey pot
CISA review manual 2014 Page number 348
http://en.wikipedia.org/wiki/Honeypot_%28computing%29
http://www.ce-infosys.com/english/free_compusec/free_compusec.aspx

QUESTION 417

An IS auditor needs to consider many factors while evaluating an encryption system. Which of the following is LEAST important factor to be considered while evaluating an encryption system?

- A. Encryption algorithm
- B. Encryption keys
- C. Key length
- D. Implementation language

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Implementation language is LEAST important as compare to other options. Encryption algorithm, encryption keys and key length are key elements of an Encryption system.

It is important to read carefully the question. The word "LEAST" was the key word. You had to find which one was LEAST important.

The following were incorrect answers:

Other options mentioned are key elements of an Encryption system

Encryption Algorithm A mathematically based function or calculation that encrypts/decrypts data

Encryption keys A piece of information that is used within an encryption algorithm (calculation) to make encryption or decryption process unique. Similar to passwords, a user needs to use the correct key to access or decipher the message into an unreadable form.

Key length A predetermined length for the key. The longer the key, the more difficult it is to compromise in brute-force attack where all possible key combinations

QUESTION 418

Which of the following statement correctly describes the difference between symmetric key encryption and asymmetric key encryption?

- A. In symmetric key encryption the same key is used for encryption and decryption where as asymmetric key uses private key for encryption and decryption
- B. In symmetric key encryption the public key is used for encryption and the symmetric key for decryption.
Where as in asymmetric key encryption the public key is used for encryption and private key is used for decryption
- C. In symmetric key encryption the same key is used for encryption and decryption where as in asymmetric key encryption the public key is used for encryption and private key is used for decryption.
- D. Both uses private key for encryption and the decryption process can be done using public key

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

There are two basic techniques for encrypting information: symmetric encryption (also called secret key encryption) and asymmetric encryption (also called public key encryption.)

Symmetric Encryption

Symmetric encryption is the oldest and best-known technique. A secret key, which can be a number, a word, or just a string of random letters, is applied to the text of a message to change the content in a particular way. This might be as simple as shifting each letter by a number of places in the alphabet. As long as both sender and recipient know the secret key, they can encrypt and decrypt all messages that use this key. Few examples of symmetric key algorithms are DES, AES, Blowfish, etc

Asymmetric Encryption

The problem with secret keys is exchanging them over the Internet or a large network while preventing them from falling into the wrong hands. Anyone who knows the secret key can decrypt the message. One answer is the usage of asymmetric encryption, in which there are two related keys, usually called a key pair. The public key is made freely available to anyone who might want to send you a message. The second key, called the private key is kept secret, so that only you know it.

Any message (text, binary files, or documents) that are encrypted using the public key can only be decrypted by the matching private key. Any message that is encrypted by using the private key can only be decrypted by using the matching public key.

This means that you do not have to worry about passing public keys over the Internet (the keys are supposed to be public).A problem with asymmetric encryption, however, is that it is slower than symmetric encryption. It requires far more processing power to both encrypt and decrypt the content of the message.

Few examples of asymmetric key algorithms are RSA, Elliptic key Cryptography (ECC), El Gamal, Differ- Hellman, etc

The following were incorrect answers:

The other options don't describe correctly the difference between symmetric key and asymmetric key encryption.

CISA review manual 2014 Page number 348 and 349

<http://support.microsoft.com/kb/246071>

QUESTION 419

Which policy helps an auditor to gain a better understanding of biometrics system in an organization?

- A. BIMS Policy
- B. BOMS Policy
- C. BMS Policy
- D. BOS Policy

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The auditor should use a Biometric Information Management System (BIMS) Policy to gain better understanding of the biometric system in use.

Management of Biometrics

Management of biometrics should address effective security for the collection, distribution and processing of biometrics data encompassing:

Data integrity, authenticity and non-repudiation

Management of biometric data across its life cycle compromised of the enrollment, transmission and storage, verification, identification, and termination process

Usage of biometric technology, including one-to-one and one-to-many matching, for identification and authentication

Application of biometric technology for internal and external, as well as logical and physical access control Encapsulation of biometric data

Security of the physical hardware used throughout the biometric data life cycle Techniques for integrity and privacy protection of biometric data.

Management should develop and approve a Biometric Information Management and Security (BIMS) policy. The auditor should use the BIMS policy to gain better understanding of the biometric system in use. With respect to testing, the auditor should make sure this policy has been developed and biometric information system is being secured appropriately.

The identification and authentication procedures for individual enrollment and template creation should be specified in BIMS policy.

The following were incorrect answers:

All other choices presented were incorrect answers because they are not valid policies.

CISA review manual 2014 Page number 331 and 332

QUESTION 420

Which of the following comparisons are used for identification and authentication in a biometric system?

- A. One-to-many for identification and authentication
- B. One-to-one for identification and authentication
- C. One-to-many for identification and one-to-one for authentication
- D. One-to-one for identification and one-to-many for authentication

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

In identification mode the system performs a one-to-many comparison against a biometric database in attempt to establish the identity of an unknown individual. The system will succeed in identifying the individual if the

comparison of the biometric sample to a template in the database falls within a previously set threshold. Identification mode can be used either for 'positive recognition' (so that the user does not have to provide any information about the template to be used) or for 'negative recognition' of the person "where the system establishes whether the person is who she (implicitly or explicitly) denies to be"

In verification (or authentication) mode the system performs a one-to-one comparison of a captured biometric with a specific template stored in a biometric database in order to verify the individual is the person they claim to be.

Management of Biometrics

Management of biometrics should address effective security for the collection, distribution and processing of biometrics data encompassing:

Data integrity, authenticity and non-repudiation

Management of biometric data across its life cycle compromised of the enrollment, transmission and storage, verification, identification, and termination process

Usage of biometric technology, including one-to-one and one-to-many matching, for identification and authentication

Application of biometric technology for internal and external, as well as logical and physical access control Encapsulation of biometric data

Security of the physical hardware used throughout the biometric data life cycle Techniques for integrity and privacy protection of biometric data.

The following were incorrect answers:

All other choices presented were incorrectly describing identification and authentication mapping.

CISA review manual 2014 Page number 331

<http://en.wikipedia.org/wiki/Biometrics>

QUESTION 421

The goal of an information system is to achieve integrity, authenticity and non-repudiation of information's sent across the network. Which of the following statement correctly describe the steps to address all three?

- A. Encrypt the message digest using symmetric key and then send the encrypted digest to receiver along with original message.
- B. Encrypt the message digest using receiver's public key and then send the encrypted digest to receiver along with original message. The receiver can decrypt the message digest using his own private key.
- C. Encrypt the message digest using sender's public key and then send the encrypted digest to the receiver along with original message. The receiver can decrypt using his own private key.
- D. Encrypt message digest using sender's private key and then send the encrypted digest to the receiver along with original message. Receiver can decrypt the same using sender's public key.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The digital signature is used to achieve integrity, authenticity and non-repudiation. In a digital signature, the sender's private key is used to encrypt the message digest of the message. Encrypting the message digest is the act of Signing the message. The receiver will use the matching public key of the sender to decrypt the Digital Signature using the sender's public key.

A digital signature (not to be confused with a digital certificate) is an electronic signature that can be used to authenticate the identity of the sender of a message or the signer of a document, and possibly to ensure that

the original content of the message or document that has been sent is unchanged. Digital signatures cannot be forged by someone else who does not possess the private key, it can also be automatically time-stamped. The ability to ensure that the original signed message arrived means that the sender cannot easily repudiate it later.

A digital signature can be used with any kind of message, whether it is encrypted or not, simply so that the receiver can be sure of the sender's identity and that the message arrived intact. A digital certificate contains the digital signature of the certificate-issuing authority so that anyone can verify that the certificate is real and has not been modified since the day it was issued.

How Digital Signature Works

Assume you were going to send the draft of a contract to your lawyer in another town. You want to give your lawyer the assurance that it was unchanged from what you sent and that it is really from you.

You copy-and-paste the contract (it's a short one!) into an e-mail note. Using special software, you obtain a message hash (mathematical summary) of the contract. You then use a private key that you have previously obtained from a public-private key authority to encrypt the hash. The encrypted hash becomes your digital signature of the message. (Note that it will be different each time you send a message.)

At the other end, your lawyer receives the message.

To make sure it's intact and from you, your lawyer makes a hash of the received message. Your lawyer then uses your public key to decrypt the message hash or summary.

If the hashes match, the received message is valid.

Below are some common reasons for applying a digital signature to communications:

Authentication

Although messages may often include information about the entity sending a message, that information may not be accurate. Digital signatures can be used to authenticate the source of messages. The importance of high assurance in the sender authenticity is especially obvious in a financial context. For example, suppose a bank's branch office sends instructions to the central office requesting a change in the balance of an account. If the central office is not convinced that such a message is truly sent from an authorized source, acting on such a request could be a serious mistake.

Integrity

In many scenarios, the sender and receiver of a message may have a need for confidence that the message has not been altered during transmission. Although encryption hides the contents of a message, it may be possible to change an encrypted message without understanding it. (Some encryption algorithms, known as nonmalleable ones, prevent this, but others do not.) However, if a message is digitally signed, any change in the message after the signature has been applied would invalidate the signature. Furthermore, there is no efficient way to modify a message and its signature to produce a new message with a valid signature, because this is still considered to be computationally infeasible by most cryptographic hash functions (see collision resistance).

Non-repudiation

Non-repudiation, or more specifically non-repudiation of origin, is an important aspect of digital signatures. By this property, an entity that has signed some information cannot at a later time deny having signed it. Similarly, access to the public key only does not enable a fraudulent party to fake a valid signature.

Note that authentication, non-repudiation, and other properties rely on the secret key not having been revoked prior to its usage. Public revocation of a key-pair is

a required ability, else leaked secret keys would continue to implicate the claimed owner of the key-pair. Checking revocation status requires an "online" check, e.g. checking a "Certificate Revocation List" or via the "Online Certificate Status Protocol". This is analogous to a vendor who receives credit-cards first checking online with the credit-card issuer to find if a given card has been reported lost or stolen.

Tip for the exam

Digital Signature does not provide confidentiality. It provides only authenticity and integrity. The sender's private key is used to encrypt the message digest to calculate the digital signature

Encryption provides only confidentiality. The receiver's public key or symmetric key is used for encryption

The following were incorrect answers:

Encrypt the message digest using symmetric key and then send the encrypted digest to receiver along with original message - Symmetric key encryption does not provide non-repudiation as symmetric key is shared between users

Encrypt the message digest using receiver's public key and then send the encrypted digest to receiver along with original message. The receiver can decrypt the message digest using his own private key - Receiver's public key is known to everyone. This will not address non-repudiation

Encrypt the message digest using sender's public key and then send the encrypted digest to the receiver along with original message. The receiver can decrypt using his own private key -The sender public key is known to everyone. If sender's key is used for encryption, then sender's private key is required to decrypt data. The receiver will not be able to decrypt the digest as receiver will not have sender's private key.

CISA review manual 2014 Page number 331

http://upload.wikimedia.org/wikipedia/commons/2/2b/Digital_Signature_diagram.svg http://en.wikipedia.org/wiki/Digital_signature

<http://searchsecurity.techtarget.com/definition/digital-signature>

QUESTION 422

Which of the following is an advantage of asymmetric crypto system over symmetric key crypto system?

- A. Performance and Speed
- B. Key Management is built in
- C. Adequate for Bulk encryption
- D. Number of keys grows very quickly

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Key management is better in asymmetric key encryption as compare to symmetric key encryption. In fact, there is no key management built within Symmetric Crypto systems. You must use the sneaker net or a trusted courier to exchange the key securely with the person you wish to communicate with.

Key management is the major issue and challenge in symmetric key encryption.

In symmetric key encryption, a symmetric key is shared between two users who wish to communicate together. As the number of users grows, the number of keys required also increases very rapidly.

For example, if a user wants to communicate with 5 different users then total number of different keys required by the user are 10. The formula for calculating total number of key required is $n(n-1)/2$ Or total number of users times total of users minus one divided by 2.

Where n is number of users communicating with each others securely.

In an asymmetric key encryption, every user will have only two keys, also referred to as a Key Pair.

Private Key Only known to the user who initially generated the key pair Public key Known to everyone, can be distributed at large

The following were incorrect answers:

Performance Symmetric key encryption performance is better than asymmetric key encryption Bulk encryption As symmetric key encryption gives better performance, symmetric key should be used for bulk data encryption

Number of keys grows very quickly - The number of keys under asymmetric grows very nicely. 1000 users would need a total of only 2000 keys, or a private and a public key for each user. Under symmetric encryption, one thousand users would need 495,000 keys to communicate securely with each others.

CISA review manual 2014 Page number 348

QUESTION 423

Which key is used by the sender of a message to create a digital signature for the message being sent?

- A. Sender's public key
- B. Sender's private key
- C. Receiver's public key
- D. Receiver's private key

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The sender private key is used to calculate the digital signature

The digital signature is used to achieve integrity, authenticity and non-repudiation. In a digital signature, the sender's private key is used to encrypt the message digest (signing) of the message and receiver need to decrypt the same using sender's public key to validate the signature.

A digital signature (not to be confused with a digital certificate) is an electronic signature that can be used to authenticate the identity of the sender of a message or the signer of a document, and possibly to ensure that the original content of the message or document that has been sent is unchanged. Digital signatures are easily transportable, cannot be imitated by someone else, and can be automatically time-stamped. The ability to ensure that the original signed message arrived means that the sender cannot easily repudiate it later.

A digital signature can be used with any kind of message, whether it is encrypted or not, simply so that the receiver can be sure of the sender's identity and that the message arrived intact. A digital certificate contains the digital signature of the certificate-issuing authority so that anyone can verify that the certificate is real. How It Works

Assume you were going to send the draft of a contract to your lawyer in another town. You want to give your lawyer the assurance that it was unchanged from what you sent and that it is really from you.

You copy-and-paste the contract (it's a short one!) into an e-mail note. Using special software, you obtain a message hash (mathematical summary) of the contract. You then use a private key that you have previously obtained from a public-private key authority to encrypt the hash. The encrypted hash becomes your digital signature of the message. (Note that it will be different each time you send a message.)

At the other end, your lawyer receives the message:

To make sure it's intact and from you, your lawyer makes a hash of the received message. Your lawyer then uses your public key to decrypt the message hash or summary. If the hashes match, the received message is valid.

Below are some common reasons for applying a digital signature to communications:

Authentication

Although messages may often include information about the entity sending a message, that information may not be accurate. Digital signatures can be used to authenticate the source of messages. When ownership of a digital signature secret key is bound to a specific user, a valid signature shows that the message was sent by that user. The importance of high confidence in sender authenticity is especially obvious in a financial context. For example, suppose a bank's branch office sends instructions to the central office requesting a change in the balance of an account. If the central office is not convinced that such a message is truly sent from an authorized source, acting on such a request could be a grave mistake.

Integrity

In many scenarios, the sender and receiver of a message may have a need for confidence that the message has not been altered during transmission. Although encryption hides the contents of a message, it may be possible to change an encrypted message without understanding it. (Some encryption algorithms, known as nonmalleable ones, prevent this, but others do not.) However, if a message is digitally signed, any change in the message after signature invalidates the signature. Furthermore, there is no efficient way to modify a message and its signature to produce a new message with a valid signature, because this is still considered to be computationally infeasible by most cryptographic hash functions (see collision resistance).

Non-repudiation

Non-repudiation, or more specifically non-repudiation of origin, is an important aspect of digital signatures. By this property, an entity that has signed some information cannot at a later time deny having signed it. Similarly, access to the public key only does not enable a fraudulent party to fake a valid signature.

Note that these authentication, non-repudiation etc. properties rely on the secret key not having been revoked prior to its usage. Public revocation of a key-pair is a required ability, else leaked secret keys would continue to implicate the claimed owner of the key-pair. Checking revocation status requires an "online" check, e.g. checking a "Certificate Revocation List" or via the "Online Certificate Status Protocol". Very roughly this is analogous to a vendor who receives credit-cards first checking online with the credit-card issuer to find if a given card has been reported lost or stolen. Of course, with stolen key pairs, the theft is often discovered only after the secret key's use, e.g., to sign a bogus certificate for espionage purposes.

Tip for the exam:

Digital Signature does not provide confidentiality. The sender's private key is used for calculating digital signature
Encryption provides only confidentiality. The receiver's public key or symmetric key is used for encryption

The following were incorrect answers:

Sender's Public key This is incorrect as receiver will require sender's private key to verify digital signature. Receiver's Public Key The digital signature provides non-repudiation. The receiver's public key is known to every one. So it can not be used for digital-signature. Receiver's public key can be used for encryption. Receiver's Private Key The sender does not know the receiver's private key. So this option is incorrect.

CISA review manual 2014 Page number 348

http://upload.wikimedia.org/wikipedia/commons/2/2b/Digital_Signature_diagram.svg http://en.wikipedia.org/wiki/Digital_signature
<http://searchsecurity.techtarget.com/definition/digital-signature>

QUESTION 424

Which of the following cryptography is based on practical application of the characteristics of the smallest

"grains" of light, the photon, the physical laws governing their generation and propagation and detection?

- A. Quantum Cryptography
- B. Elliptical Curve Cryptography (ECC)
- C. Symmetric Key Cryptography
- D. Asymmetric Key Cryptography

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Quantum cryptography is based on a practical application of the characteristics of the smallest "grain" of light, photons and on physical laws governing their generation, propagation and detection. Quantum cryptography is the next generation of cryptography that may solve some of the existing problem associated with current cryptographic systems, specifically the random generation and secure distribution of symmetric cryptographic keys. Initial commercial usage has already started now that the laboratory research phase has been completed.

Quantum cryptography is based on a practical application of the characteristics of the smallest "grain" of light, photons and on physical laws governing their generation, propagation and detection. Quantum cryptography is the next generation of cryptography that may solve some of the existing problem associated with current cryptographic systems, specifically the random generation and secure distribution of symmetric cryptographic keys. Initial commercial usage has already started now that the laboratory research phase has been completed.

The following were incorrect answers: Elliptic Key Cryptography(ECC) - A variant and more efficient form of a public key cryptography (how to manage more security out of minimum resources) gaining prominence is the ECC. ECC works well on a network computer requires strong cryptography but have some limitation such as bandwidth and processing power. This is even more important with devices such as smart cards, wireless phones and other mobile devices. It is believed that ECC demands less computational power and, therefore offers more security per bit. For example, an ECC with a 160-bit key offer the same security as an RSA based system with a 1024-bit key.

Symmetric Encryption- Symmetric encryption is the oldest and best-known technique. A secret key, which can be a number, a word, or just a string of random letters, is applied to the text of a message to change the content in a particular way. This might be as simple as shifting each letter by a number of places in the alphabet. As long as both sender and recipient know the secret key, they can encrypt and decrypt all messages that use this key.

The problem with secret keys is exchanging them over the Internet or a large network while preventing them from falling into the wrong hands. Anyone who knows the secret key can decrypt the message.

Asymmetric encryption -In which there are two related keys--a key pair. A public key is made freely available to anyone who might want to send you a message. A second, private key is kept secret, so that only you know it.

Any message (text, binary files, or documents) that are encrypted by using the public key can only be decrypted by applying the same algorithm, but by using the matching private key. Any message that is encrypted by using the private key can only be decrypted by using the matching public key.

This means that you do not have to worry about passing public keys over the Internet (the keys are supposed to be public). A problem with asymmetric encryption,

however, is that it is slower than symmetric encryption. It requires far more processing power to both encrypt and decrypt the content of the message.
CISA review manual 2014 Page number 349 and 350

<http://support.microsoft.com/kb/246071>

QUESTION 425

Which of the following cryptography demands less computational power and offers more security per bit?

- A. Quantum cryptography
- B. Elliptic Curve Cryptography (ECC)
- C. Symmetric Key Cryptography
- D. Asymmetric Key Cryptography

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

ECC demands less computational power and, therefore offers more security per bit. For example, an ECC with a 160-bit key offer the same security as an RSA based system with a 1024-bit key.

ECC is a variant and more efficient form of a public key cryptography (how to manage more security out of minimum resources) gaining prominence is the ECC. ECC works well on a network computer requires strong cryptography but have some limitation such as bandwidth and processing power. This is even more important with devices such as smart cards, wireless phones and other mobile devices.

The following were incorrect answers:

Quantum Cryptography - Quantum cryptography is based on a practical application of the characteristics of the smallest "grain" of light, photons and on physical laws governing their generation, propagation and detection. Quantum cryptography is the next generation of cryptography that may solve some of the existing problem associated with current cryptographic systems, specifically the random generation and secure distribution of symmetric cryptographic keys. Initial commercial usage has already started now that the laboratory research phase has been completed.

Symmetric Encryption - Symmetric encryption is the oldest and best-known technique. A secret key, which can be a number, a word, or just a string of random letters, is applied to the text of a message to change the content in a particular way. This might be as simple as shifting each letter by a number of places in the alphabet. As long as both sender and recipient know the secret key, they can encrypt and decrypt all messages that use this key.

Asymmetric Encryption - The problem with secret keys is exchanging them over the Internet or a large network while preventing them from falling into the wrong hands. Anyone who knows the secret key can decrypt the message. One answer is asymmetric encryption, in which there are two related keys--a key pair. A public key is made freely available to anyone who might want to send you a message. A second, private key is kept secret, so that only you know it. Any message (text, binary files, or documents) that are encrypted by using the public key can only be decrypted by applying the same algorithm, but by using the matching private key. Any message that is encrypted by using the private key can only be decrypted by using the matching public key. This means that you do not have to worry about passing public keys over the Internet (the keys are supposed to be public). A problem with asymmetric encryption, however, is that it is slower than symmetric encryption. It requires far more processing power to both encrypt and decrypt the content of the message.

CISA review manual 2014 Page number 349 and 350

<http://support.microsoft.com/kb/246071>

QUESTION 426

Which of the following is a form of Hybrid Cryptography where the sender encrypts the bulk of the data using Symmetric Key cryptography and then communicates securely a copy of the session key to the receiver?

- A. Digital Envelope
- B. Digital Signature
- C. Symmetric key encryption
- D. Asymmetric

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A Digital Envelope is used to send encrypted information using symmetric keys, and the relevant session key along with it. It is a secure method to send electronic document without compromising the data integrity, authentication and non-repudiation, which were obtained with the use of symmetric keys.

A Digital envelope mechanism works as follows:

The symmetric key, which is used to encrypt the bulk of the data or message can be referred to as session key. It is simply a symmetric key picked randomly in the key space. In order for the receiver to have the ability to decrypt the message, the session key must be sent to the receiver.

This session key cannot be sent in clear text to the receiver, it must be protected while in transit, else anyone who has access to the network could have access to the key and confidentiality can easily be compromised. Therefore, it is critical to encrypt and protect the session key before sending it to the receiver. The session key is encrypted using receiver's public key. Thus providing confidentiality of the key. The encrypted message and the encrypted session key are bundled together and then sent to the receiver who, in turn opens the session key with the receiver matching private key. The session key is then applied to the message to get it in plain text.

The process of encrypting bulk data using symmetric key cryptography and encrypting the session key with a public key algorithm is referred to as a digital envelope. Sometimes people refer to it as Hybrid Cryptography as well.

The following were incorrect answers:

Digital-signature A digital signature is an electronic identification of a person or entity created by using public key algorithm and intended to verify to recipient the integrity of the data and the identity of the sender. Applying a digital signature consists of two simple steps, first you create a message digest, then you encrypt the message digest with the sender's private key. Encrypting the message digest with the private key is the act of signing the message.

Symmetric Key Encryption - Symmetric encryption is the oldest and best-known technique. A secret key, which can be a number, a word, or just a string of random letters, is applied to the text of a message to change the content in a particular way. This might be as simple as shifting each letter by a number of places in the alphabet. As long as both sender and recipient know the secret key, they can encrypt and decrypt all messages that use this key.

Asymmetric Key Encryption - The term "asymmetric" stems from the use of different keys to perform these opposite functions, each the inverse of the other as contrasted with conventional ("symmetric") cryptography which relies on the same key to perform both. Public-key algorithms are based on mathematical problems which currently admit no efficient solution that are inherent in certain integer factorization, discrete logarithm, and elliptic curve relationships. It is computationally easy for a user to generate their own public and private key-pair and to use them for encryption and decryption. The strength lies in the fact that it is "impossible" (computationally unfeasible) for a properly generated private key to be determined from its corresponding public key. Thus the public key may be published without compromising security, whereas the

private key must not be revealed to anyone not authorized to read messages or perform digital signatures. Public key algorithms, unlike symmetric key algorithms, do not require a secure initial exchange of one (or more) secret keys between the parties.

CISA review manual 2014 Page number 350 and 351
http://en.wikipedia.org/wiki/Public-key_cryptography

QUESTION 427

How does the digital envelop work? What are the correct steps to follow?

- A. You encrypt the data using a session key and then encrypt session key using private key of a sender
- B. You encrypt the data using the session key and then you encrypt the session key using sender's public key
- C. You encrypt the data using the session key and then you encrypt the session key using the receiver's public key
- D. You encrypt the data using the session key and then you encrypt the session key using the receiver's private key

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The process of encrypting bulk data using symmetric key cryptography and then encrypting the session key using public key algorithm is referred as a digital envelope.

A Digital Envelope is used to send encrypted information using symmetric crypto cipher and then key session along with it. It is secure method to send electronic document without compromising the data integrity, authentication and non-repudiation, which were obtained with the use of symmetric keys.

A Digital envelope mechanism works as follows:

The symmetric key used to encrypt the message can be referred to as session key. The bulk of the message would take advantage of the high speed provided by Symmetric Cipher. The session key must then be communicated to the receiver in a secure way to allow the receiver to decrypt the message. If the session key is sent to receiver in the plain text, it could be captured in clear text over the network and anyone could access the session key which would lead to confidentiality being compromised. Therefore it is critical to encrypt the session key with the receiver public key before sending it to the receiver. The receiver's will use their matching private key to decrypt the session key which then allow them to decrypt the message using the session key.

The encrypted message and the encrypted session key are sent to the receiver who, in turn decrypts the session key with the receiver's private key. The session key is then applied to the message cipher text to get the plain text.

The following were incorrect answers:

You encrypt the data using a session key and then encrypt session key using private key of a sender - If the session key is encrypted using sender's private key, it can be decrypted only using sender's public key. The sender's public key is known to everyone so anyone can decrypt session key and message.

You encrypt the data using the session key and then you encrypt the session key using sender's public key - If the session key is encrypted by using sender's public key then only sender can decrypt the session key using his/her own private key and receiver will not be able to decrypt the same.

You encrypt the data using the session key and then you encrypt the session key using the receiver's private key - Sender should not have access to receiver's private key. This is not a valid option.

CISA review manual 2014 Page number 350 and 351

QUESTION 428

Which of the following is NOT a true statement about public key infrastructure (PKI)?

- A. The Registration authority role is to validate and issue digital certificates to end users
- B. The Certificate authority role is to issue digital certificates to end users
- C. The Registration authority (RA) acts as a verifier for Certificate Authority (CA)
- D. Root certificate authority's certificate is always self-signed

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The word NOT is the keyword used in the question. We need to find out the invalid statement from the options.

A PKI (public key infrastructure) enables users of a basically unsecure public network such as the Internet to securely and privately exchange data and money through the use of a public and a private cryptographic key pair that is obtained and shared through a trusted authority. The public key infrastructure provides for a digital certificate that can identify an individual or an organization and directory services that can store and, when necessary, revoke the certificates. Although the components of a PKI are generally understood, a number of different vendor approaches and services are emerging. Meanwhile, an Internet standard for PKI is being worked on.

The public key infrastructure assumes the use of public key cryptography, which is the most common method on the Internet for authenticating a message sender or encrypting a message. Traditional cryptography has usually involved the creation and sharing of a secret key for the encryption and decryption of messages. This secret or private key system has the significant flaw that if the key is discovered or intercepted by someone else, messages can easily be decrypted. For this reason, public key cryptography and the public key infrastructure is the preferred approach on the Internet. (The private key system is sometimes known as symmetric cryptography and the public key system as asymmetric cryptography.)

A public key infrastructure consists of:

A certificate authority (CA) that issues and verifies digital certificate. A certificate includes the public key or information about the public key

A registration authority (RA) that acts as the verifier for the certificate authority before a digital certificate is issued to a requester

A Subscriber is the end user who wish to get digital certificate from certificate authority.

The following were incorrect answers:

The Certificate authority role is to issue digital certificates to end users - This is a valid statement as the job of a certificate authority is to issue a digital certificate to end user.

The Registration authority (RA) acts as a verifier for Certificate Authority (CA) - This is a valid statement as registration authority acts as a verifier for certificate authority

Root certificate authority's certificate is always self-signed - This is a valid statement as the root certificate authority's certificate is always self-signed.
<http://searchsecurity.techtarget.com/definition/PKI>

QUESTION 429

Which of the following functionality is NOT supported by SSL protocol?

- A. Confidentiality
- B. Integrity
- C. Authentication
- D. Availability

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The NOT is a keyword used in this question. You need to find out the functionality which is NOT provided by SSL protocol. The SSL protocol provides:

Confidentiality

Integrity

Authentication, e.g. between client and server

Non-repudiation

For CISA exam you should know the information below about Secure Socket Layer (SSL) and Transport Layer Security (TLS)

These are cryptographic protocols which provide secure communication on Internet. There are only slight difference between SSL 3.0 and TLS 1.0. For general concept both are called SSL.

SSL is session-connection layer protocol widely used on Internet for communication between browser and web servers, where any amount of data is securely transmitted while a session is established. SSL provides end point authentication and communication privacy over the Internet using cryptography. In typical use, only the server is authenticated while client remains unauthenticated. Mutual authentication requires PKI development to clients. The protocol allows application to communicate in a way designed to prevent eavesdropping, tampering and message forging.

SSL involves a number of basic phases

Peer negotiation for algorithm support

Public-key, encryption based key exchange and certificate based authentication Symmetric cipher based traffic encryption.

SSL runs on a layer beneath application protocol such as HTTP, SMTP and Network News Transport Protocol (NNTP) and above the TCP transport protocol, which forms part of TCP/IP suite.

SSL uses a hybrid hashed, private and public key cryptographic processes to secure transmission over the INTERNET through a PKI.

The SSL handshake protocol is based on the application layer but provides for the security of the communication session too. It negotiates the security parameter for each communication section. Multiple session can belong to one SSL session and the participating in one session can take part in multiple simultaneous sessions.

The following were incorrect answers:

Confidentiality - It is supported by the SSL Protocol

Integrity -It is supported by the SSL Protocol

Authentication - It is supported by the SSL protocol

CISA review manual 2014 Page number 352

QUESTION 430

Which of the following statement correctly describes one way SSL authentication between a client (e.g. browser) and a server (e.g. web server)?

- A. Only the server is authenticated while client remains unauthenticated
- B. Only the client is authenticated while server remains authenticated
- C. Client and server are authenticated
- D. Client and server are unauthenticated

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

In one way authentication only server needs to be authenticated where as in mutual authentication both the client and the server needs to be authenticated.

For CISA exam you should know the information below about Secure Socket Layer (SSL) and Transport Layer Security (TLS)

These are cryptographic protocols which provide secure communication on Internet. There are only slight difference between SSL 3.0 and TLS 1.0. For general concept both are called SSL.

SSL is session-connection layer protocol widely used on Internet for communication between browser and web servers, where any amount of data is securely transmitted while a session is established. SSL provides end point authentication and communication privacy over the Internet using cryptography. In typical use, only the server is authenticated while client remains unauthenticated. Mutual authentication requires PKI development to clients. The protocol allows application to communicate in a way designed to prevent eavesdropping, tampering and message forging.

SSL involves a number of basic phases

Peer negotiation for algorithm support

Public-key, encryption based key exchange and certificate based authentication Symmetric cipher based traffic encryption.

SSL runs on a layer beneath application protocol such as HTTP, SMTP and Network News Transport Protocol (NNTP) and above the TCP transport protocol, which forms part of TCP/IP suite.

SSL uses a hybrid hashed, private and public key cryptographic processes to secure transmission over the INTERNET through a PKI.

The SSL handshake protocol is based on the application layer but provides for the security of the communication session too. It negotiates the security parameter for each communication section. Multiple session can belong to one SSL session and the participating in one session can take part in multiple simultaneous sessions.

The following were incorrect answers:

The other choices presented in the options are not valid as in one way authentication only server needs to be authenticated where as client will remain unauthenticated.

QUESTION 431

Which of the following statement correctly describes difference between SSL and S/HTTP?

- A. Both works at application layer of OSI model
- B. SSL works at transport layer where as S/HTTP works at application layer of OSI model
- C. Both works at transport layer
- D. S/HTTP works at transport layer where as SSL works at the application layer of OSI model

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

For your exam you should know below information about S/HTTP and SSL protocol:

Secure Hypertext Transfer Protocol (S/HTTP) -As an application layer protocol, S/HTTP transmits individual messages or pages securely between a web client and server by establishing SSL-type connection. Using the https:// designation in the URL, instead of the standard http://, directs the message to a secure port number rather than the default web port address. This protocol utilizes SSL secure features but does so as a message rather than the session-oriented protocol.

Secure Socket Layer (SSL) and Transport Layer Security (TLS) - These are cryptographic protocols which provide secure communication on Internet. There are only slight difference between SSL 3.0 and TLS 1.0. For general concept both are called SSL. SSL is session-connection layer protocol widely used on Internet for communication between browser and web servers, where any amount of data is securely transmitted while a session is established. SSL provides end point authentication and communication privacy over the Internet using cryptography. In typical use, only the server is authenticated while client remains unauthenticated. Mutual authentication requires PKI development to clients. The protocol allows application to communicate in a way designed to prevent eavesdropping, tampering and message forging.

SSL involves a number of basic phases

Peer negotiation for algorithm support

Public-key, encryption based key exchange and certificate based authentication Symmetric cipher based traffic encryption.

SSL runs on a layer beneath application protocol such as HTTP, SMTP and Network News Transport Protocol (NNTP) and above the TCP transport protocol, which forms part of TCP/IP suite.

SSL uses a hybrid hashed, private and public key cryptographic processes to secure transmission over the INTERNET through a PKI.

The SSL handshake protocol is based on the application layer but provides for the security of the communication session too. It negotiates the security parameter for each communication section. Multiple session can belong to one SSL session and the participating in one session can take part in multiple simultaneous sessions.

The following were incorrect answers:

The other choices presented in the options are not valid as SSL works at transport layer where as S/HTTP works at application layer of OSI model.

CISA review manual 2014 Page number 352

QUESTION 432

Which of the following is a standard secure email protection protocol?

- A. S/MIME
- B. SSH
- C. SET
- D. S/HTTP

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Secure Multipurpose Internet Mail Extension (S/MIME) is a standard secure email protocol that authenticates the identity of the sender and receiver, verifies message integrity, and ensures the privacy of message's content's, including attachments.

The following were incorrect answers:

SSH A client server program that opens a secure, encrypted command-line shell session from the Internet for remote logon. Similar to a VPN, SSH uses strong cryptography to protect data, including password, binary files and administrative commands, transmitted between system on a network. SSH is typically implemented between two parties by validating each other's credential via digital certificates. SSH is useful in securing Telnet and FTP services, and is implemented at the application layer, as opposed to operating at network layer (IPSec Implementation)

SET SET is a protocol developed jointly by VISA and Master Card to secure payment transaction among all parties involved in credit card transactions among all parties involved in credit card transactions on behalf of cardholders and merchants. As an open system specification, SET is a application-oriented protocol that uses trusted third party's encryption and digital-signature process, via PKI infrastructure of trusted third party institutions, to address confidentiality of information, integrity of data, cardholders authentication, merchant authentication and interoperability.

Secure Hypertext Transfer Protocol (S/HTTP) As an application layer protocol, S/HTTP transmits individual messages or pages securely between a web client and server by establishing SSL-type connection. Using the https:// designation in the URL, instead of the standard http://, directs the message to a secure port number rather than the default web port address. This protocol utilizes SSL secure features but does so as a message rather than the session-oriented protocol. CISA review manual 2014 Page number 352 and 353

QUESTION 433

Which of the following statement correctly describes the differences between tunnel mode and transport mode of the IPSec protocol?

- A. In transport mode the ESP is encrypted where as in tunnel mode the ESP and its header's are encrypted
- B. In tunnel mode the ESP is encrypted where as in transport mode the ESP and its header's are encrypted
- C. In both modes (tunnel and transport mode) the ESP and its header's are encrypted
- D. There is no encryption provided when using ESP or AH

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

ESP can be used to provide confidentiality, data origin authentication, connectionless integrity, an anti-replay service (a form of partial sequence integrity), and (limited) traffic flow confidentiality. The set of services provided depends on options selected at the time of Security Association (SA) establishment and on the location of the implementation in a network topology. For your exam you should know the information below about the IPsec protocol:

The IP network layer packet security protocol establishes VPNs via transport and tunnel mode encryption methods.

For the transport method, the data portion of each packet is encrypted, encryption within IPSEC is referred to as the encapsulation security payload (ESP), it is ESP that provides confidentiality over the process. In the tunnel mode, the ESP payload and its header's are encrypted. To achieve non-repudiation, an additional authentication header (AH) is applied.

In establishing IPsec sessions in either mode, Security Associations (SAs) are established. SAs defines which security parameters should be applied between communicating parties as encryption algorithms, key initialization vector, life span of keys, etc. Within either ESP or AH header, respectively. An SAs is established when a 32-bit security parameter index (SPI) field is defined within the sending host. The SPI is unique identifier that enables the sending host to reference the security parameter to apply, as specified, on the receiving host.

IPsec can be made more secure by using asymmetric encryption through the use of Internet Security Association and Key Management Protocol/Oakley (ISAKMP/Oakley), which allows automated key management, use of public keys, negotiation, establishment, modification and deletion of SAs and attributes. For authentication, the sender uses digital certificates. The connection is made secure by supporting the generation, authentication, distribution of the SAs and the cryptographic keys.

The following were incorrect answers:

The other options presented are invalid as the transport mode encrypts ESP and the tunnel mode encrypts ESP and its header's.
CISA review manual 2014 Page number 353

QUESTION 434

Which of the following is the unique identifier within an IPsec packet that enables the sending host to reference the security parameter to apply?

- A. SPI
- B. SA
- C. ESP
- D. AH

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The Security Parameter Index (SPI) is the unique identifier that enables the sending host to reference the security parameter to apply in order to decrypt the packet.

For your exam you should know the information below about the IPsec protocol:

The IP network layer packet security protocol establishes VPNs via transport and tunnel mode encryption methods.

For the transport method, the data portion of each packet is encrypted, encryption within IPSEC is referred to as the encapsulation security payload (ESP), it is ESP that provides confidentiality over the process. In the tunnel mode, the ESP payload and its header's are encrypted. To achieve non-repudiation, an additional authentication header (AH) is applied.

In establishing IPsec sessions in either mode, Security Associations (SAs) are established. SAs defines which security parameters should be applied between communicating parties as encryption algorithms, key initialization vector, life span of keys, etc. Within either ESP or AH header, respectively. An SAs is established when a 32-bit security parameter index (SPI) field is defined within the sending host. The SPI is unique identifier that enables the sending host to reference the security parameter to apply, as specified, on the receiving host.

IPsec can be made more secure by using asymmetric encryption through the use of Internet Security Association and Key Management Protocol/Oakley (ISAKMP/Oakley), which allows automated key management, use of public keys, negotiation, establishment, modification and deletion of SAs and attributes. For authentication, the sender uses digital certificates. The connection is made secure by supporting the generation, authentication, distribution of the SAs and the cryptographic keys.

The following were incorrect answers:

SA Security Association (SA) defines which security parameters should be applied between communicating parties as encryption algorithms, key initialization vector, life span of keys, etc. ESP Encapsulation Security Payload (ESP) is used to support authentication of sender and encryption of data
AH Authentication Header allows authentication of a sender of a data.
CISA review manual 2014 Page number 353

QUESTION 435

Within IPSEC which of the following defines security parameters which should be applied between communicating parties such as encryption algorithms, key initialization vector, life span of keys, etc?

- A. Security Parameter Index (SPI)
- B. Security Association (SA)
- C. Encapsulation Security Payload (ESP)
- D. Authentication Header (AH)

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Security Association (SA)s defines which security parameters should be applied between communication parties as encryption algorithms, key initialization vector, life span of keys, etc.

For your exam you should know the information below about the IPsec protocol:

The IP network layer packet security protocol establishes VPNs via transport and tunnel mode encryption methods.

For the transport method, the data portion of each packet is encrypted, encryption within IPSEC is referred to as the encapsulation security payload (ESP), it is ESP that provides confidentiality over the process.

In the tunnel mode, the ESP payload and its header's are encrypted. To achieve non-repudiation, an additional authentication header (AH) is applied.

In establishing IPsec sessions in either mode, Security Associations (SAs) are established. SAs defines which security parameters should be applied between

communicating parties as encryption algorithms, key initialization vector, life span of keys, etc. Within either ESP or AH header, respectively. An SAs is established when a 32-bit security parameter index (SPI) field is defined within the sending host. The SPI is unique identifier that enables the sending host to reference the security parameter to apply, as specified, on the receiving host.

IPSec can be made more secure by using asymmetric encryption through the use of Internet Security Association and Key Management Protocol/Oakley (ISAKMP/Oakley), which allows automated key management, use of public keys, negotiation, establishment, modification and deletion of SAs and attributes. For authentication, the sender uses digital certificates. The connection is made secure by supporting the generation, authentication, distribution of the SAs and the cryptographic keys.

The following were incorrect answers:

Security Parameter Index (SPI) A Security Parameter Index (SPI) is an unique identifier that enables the sending host to reference the security parameters to apply.

Encapsulation Security Payload (ESP) Encapsulation Security Payload (ESP) is used support authentication of sender and encryption of data.

Authentication Header(AH) Authentication Header allows authentication of a sender of a data.
CISA review manual 2014 Page number 353

QUESTION 436

Which of the following statement correctly describes the difference between IPSec and SSH protocols?

- A. IPSec works at the transport layer where as SSH works at the network layer of an OSI Model
- B. IPSec works at the network layer where as SSH works at the application layer of an OSI Model
- C. IPSec works at the network layer and SSH works at the transport layer of an OSI Model
- D. IPSec works at the transport layer and SSH works at the network layer of an OSI Model

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

For CISA exam you should know below information about SSH and IPSec protocol

SSH A client server program that opens a secure, encrypted command-line shell session from the Internet for remote logon. Similar to a VPN, SSH uses strong cryptography to protect data, including password, binary files and administrative commands, transmitted between system on a network. SSH is typically implemented between two parties by validating each other's credential via digital certificates. SSH is useful in securing Telnet and FTP services, and is implemented at the application layer, as opposed to operating at network layer (IPSec Implementation)

IPSec The IP network layer packet security protocol establishes VPNs via transport and tunnel mode encryption methods. For the transport method, the data portion of each packet referred to as the encapsulation security payload(ESP) is encrypted, achieving confidentiality over a process. In the tunnel mode, the ESP

payload and its header's are encrypted. To achieve non-repudiation, an additional authentication header (AH) is applied. In establishing IPSec sessions in either mode, Security Association (SAs) are established. SAs defines which security parameters should be applied between communication parties as encryption algorithms, key initialization vector, life span of keys, etc. Within either ESP or AH header, respectively. An SAs is established when a 32-bit security parameter index (SPI) field is defined within the sending host. The SPI is unique identifier that enables the sending host to reference the security parameter to apply, as specified, on the receiving host. IPSec can be made more secure by using asymmetric encryption through the use of Internet Security Association and Key Management Protocol/Oakley (ISAKMP/Oakley), which allows the key management, use of public keys, negotiation, establishment, modification and deletion of SAs and attributes. For authentication, the sender uses digital certificates. The connection is made secure by supporting the generation, authentication, distribution of the SAs and those of the cryptographic keys.

The following were incorrect answers:

The other options presented are invalid as IPSec works at network layer where as SSH works at application layer of an OSI Model.
CISA review manual 2014 Page number 352 and 353

QUESTION 437

Which of the following protocol is developed jointly by VISA and Master Card to secure payment transactions among all parties involved in credit card transactions on behalf of cardholders and merchants?

- A. S/MIME
- B. SSH
- C. SET
- D. S/HTTP

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Secure Electronic Transaction(SET) is a protocol developed jointly by VISA and Master Card to secure payment transaction among all parties involved in credit card transactions among all parties involved in credit card transactions on behalf of cardholders and merchants. As an open system specification, SET is an application-oriented protocol that uses trusted third party's encryption and digital-signature process, via PKI infrastructure of trusted third party institutions, to address confidentiality of information, integrity of data, cardholders authentication, merchant authentication and interoperability.

The following were incorrect answers:

S/MIME Secure Multipurpose Internet Mail Extension (S/MIME) is a standard secure email protocol that authenticates the identity of the sender and receiver, verifies message integrity, and ensures the privacy of message's content's, including attachments.

SSH A client server program that opens a secure, encrypted command-line shell session from the Internet for remote logon. Similar to a VPN, SSH uses strong cryptography to protect data, including password, binary files and administrative commands, transmitted between system on a network. SSH is typically implemented between two parties by validating each other's credential via digital certificates. SSH is useful in securing Telnet and FTP services, and is implemented at the application layer, as opposed to operating at network layer (IPSec Implementation)

Secure Hypertext Transfer Protocol (S/HTTP) -As an application layer protocol, S/HTTP transmits individual messages or pages securely between a web client and server by establishing SSL-type connection. Using the https:// designation in the URL, instead of the standard http://, directs the message to a secure port number

rather than the default web port address. This protocol utilizes SSL secure features but does so as a message rather than the session-oriented protocol.
CISA review manual 2014 Page number 352 and 353

QUESTION 438

An auditor needs to be aware of technical controls which are used to protect computer from malware. Which of the following technical control interrupts DoS and ROM BIOS call and look for malware like action?

- A. Scanners
- B. Active Monitors
- C. Immunizer
- D. Behavior blocker

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Active monitors interpret DoS and read-only memory (ROM) BIOS calls, looking for malware like actions. Active monitors can be problematic because they can not distinguish between a user request and a program or a malware request. As a result, users are asked to confirm actions, including formatting a disk or deleting a file or set of files.

For CISA exam you should know below mentioned different kinds of malware Controls

A. Scanners Look for sequences of bit called signature that are typical malware programs.

The two primary types of scanner are

1. Malware mask or Signatures Anti-malware scanners check files, sectors and system memory for known and new (unknown to scanner) malware, on the basis of malware masks or signatures. Malware masks or signature are specific code strings that are recognized as belonging to malware. For polymorphic malware, the scanner sometimes has algorithms that check for all possible combinations of a signature that could exist in an infected file.

2. Heuristic Scanner Analyzes the instructions in the code being scanned and decide on the basis of statistical probabilities whether it could contain malicious code. Heuristic scanning result could indicate that malware may be present, that is possibly infected. Heuristic scanner tend to generate a high level false positive errors (they indicate that malware may be present when, in fact, no malware is present). Scanners examines memory disk- boot sector, executables, data files, and command files for bit pattern that match a known malware. Scanners, therefore, need to be updated periodically to remain effective.

B. Immunizers Defend against malware by appending sections of themselves to files sometime in the same way Malware append themselves. Immunizers continuously check a file for changes and report changes as possible malware behavior. Other types of Immunizers are focused to a specific malware and work by giving the malware the impression that the malware has already infected to the computer. This method is not always practical since it is not possible to immunize file against all known malware.

C. Behavior Blocker Focus on detecting potential abnormal behavior such as writing to the boot sector or the master boot record, or making changes to executable files. Blockers can potentially detect malware at an early stage. Most hardware based anti-malware mechanism are based on this concept.

D. Integrity CRC checker Compute a binary number on a known malware free program that is then stored in a database file. The number is called Cyclic Redundancy Check (CRC). On subsequent scans, when that program is called to execute, it checks for changes to the file as compare to the database and report possible

infection if changes have occurred. A match means no infection; a mismatch means change in the program has occurred. A change in the program could mean malware within it. These scanners are effective in detecting infection; however, they can do so only after infection has occurred. Also, a CRC checker can only detect subsequent changes to files, because they assume files are malware free in the first place. Therefore, they are ineffective against new files that are malware infected and that are not recorded in the database. Integrity checker take advantage of the fact that executable programs and boot sectors do not change often, if at all.

The following were incorrect answers:

Scanners Look for sequences of bit called signature that are typical malware programs.

Immunizers Defend against malware by appending sections of themselves to files sometime in the same way Malware append themselves. Immunizers continuously check a file for changes and report changes as possible malware behavior.

Behavior Blocker Focus on detecting potential abnormal behavior such as writing to the boot sector or the master boot record, or making changes to executable files. Blockers can potentially detect malware at an early stage. Most hardware based anti-malware mechanism are based on this concept.
CISA review manual 2014 Page number 354 and 355

QUESTION 439

Which are the two primary types of scanner used for protecting against Malware?

- A. Malware mask/signatures and Heuristic Scanner
- B. Active and passive Scanner
- C. Behavioral Blockers and immunizer Scanner
- D. None of the above

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Scanners Look for sequences of bit called signature that are typical malware programs.

The two primary types of scanner are

1. Malware mask or Signatures Anti-malware scanners check files, sectors and system memory for known and new (unknown to scanner) malware, on the basis of malware masks or signatures. Malware masks or signature are specific code strings that are recognized as belonging to malware. For polymorphic malware, the scanner sometimes has algorithms that check for all possible combinations of a signature that could exist in an infected file.

2. Heuristic Scanner Analyzes the instructions in the code being scanned and decide on the basis of statistical probabilities whether it could contain malicious code. Heuristic scanning result could indicate that malware may be present, that is possibly infected. Heuristic scanner tend to generate a high level false positive errors (they indicate that malware may be present when, in fact, no malware is present) Scanner examines memory disk- boot sector, executables, data files, and command files for bit pattern that match a known malware. Scanners, therefore, need to be updated periodically to remain effective.

For CISA exam you should know below mentioned different kinds of malware Controls

A. Active Monitors Active monitors interpret DOS and read-only memory (ROM) BIOS calls, looking for

malware like actions. Active monitors can be problematic because they can not distinguish between a user request and a program or a malware request. As a result, users are asked to confirm actions, including formatting a disk or deleting a file or set of files.

B. Immunizers Defend against malware by appending sections of themselves to files sometime in the same way Malware append themselves. Immunizers continuously check a file for changes and report changes as possible malware behavior. Other types of Immunizers are focused to a specific malware and work by giving the malware the impression that the malware has already infected to the computer. This method is not always practical since it is not possible to immunize file against all known malware.

C. Behavior Blocker Focus on detecting potential abnormal behavior such as writing to the boot sector or the master boot record, or making changes to executable files. Blockers can potentially detect malware at an early stage. Most hardware based anti-malware mechanism are based on this concept.

D. Integrity CRC checker Compute a binary number on a known malware free program that is then stored in a database file. The number is called Cyclic Redundancy Check (CRC). On subsequent scans, when that program is called to execute, it checks for changes to the file as compare to the database and report possible infection if changes have occurred. A match means no infection; a mismatch means change in the program has occurred. A change in the program could mean malware within it. These scanners are effective in detecting infection; however, they can do so only after infection has occurred. Also, a CRC checker can only detect subsequent changes to files, because they assume files are malware free in the first place. Therefore, they are ineffective against new files that are malware infected and that are not recorded in the database. Integrity checker take advantage of the fact that executable programs and boot sectors do not change often, if at all.

The following were incorrect answers:

The other options presented are not a valid primary types of scanner.
CISA review manual 2014 Page number 354 and 355

QUESTION 440

Which of the following malware technical fool's malware by appending section of themselves to files somewhat in the same way that file malware appends themselves?

- A. Scanners
- B. Active Monitors
- C. Immunizer
- D. Behavior blocker

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Immunizers defend against malware by appending sections of themselves to files sometime in the same way Malware append themselves. Immunizers continuously check a file for changes and report changes as possible malware behavior. Other type of Immunizers are focused to a specific malware and work by giving the malware the impression that the malware has already infected to the computer. This method is not always practical since it is not possible to immunize file against all known malware.

For your exam you should know below mentioned different kinds of malware Controls

A. Scanners Look for sequences of bit called signature that are typical malware programs.
The two primary types of scanner are

1. Malware mask or Signatures Anti-malware scanners check files, sectors and system memory for known and new (unknown to scanner) malware, on the basis of malware masks or signatures. Malware masks or signature are specific code strings that are recognized as belonging to malware. For polymorphic malware, the scanner sometimes has algorithms that check for all possible combinations of a signature that could exist in an infected file.
2. Heuristic Scanner Analyzes the instructions in the code being scanned and decide on the basis of statistical probabilities whether it could contain malicious code. Heuristic scanning result could indicate that malware may be present, that is possibly infected. Heuristic scanner tend to generate a high level false positive errors (they indicate that malware may be present when, in fact, no malware is present) Scanner examines memory disk- boot sector, executables, data files, and command files for bit pattern that match a known malware. Scanners, therefore, need to be updated periodically to remain effective.

B. Immunizers Defend against malware by appending sections of themselves to files sometime in the same way Malware append themselves. Immunizers continuously check a file for changes and report changes as possible malware behavior. Other type of Immunizers are focused to a specific malware and work by giving the malware the impression that the malware has already infected to the computer. This method is not always practical since it is not possible to immunize file against all known malware.

C. Behavior Blocker Focus on detecting potential abnormal behavior such as writing to the boot sector or the master boot record, or making changes to executable files. Blockers can potentially detect malware at an early stage. Most hardware based anti-malware mechanism are based on this concept. D. Integrity CRC checker Compute a binary number on a known malware free program that is then stored in a database file. The number is called Cyclic Redundancy Check (CRC). On subsequent scans, when that program is called to execute, it checks for changes to the file as compare to the database and report possible infection if changes have occurred. A match means no infection; a mismatch means change in the program has occurred. A change in the program could mean malware within it. These scanners are effective in detecting infection; however, they can do so only after infection has occurred. Also, a CRC checker can only detect subsequent changes to files, because they assume files are malware free in the first place. Therefore, they are ineffective against new files that are malware infected and that are not recorded in the database. Integrity checker take advantage of the fact that executable programs and boot sectors do not change often, if at all.

E. Active Monitors Active monitors interpret DOS and read-only memory (ROM) BIOS calls, looking for malware like actions. Active monitors can be problematic because they can not distinguish between a user request and a program or a malware request. As a result, users are asked to confirm actions, including formatting a disk or deleting a file or set of files.

The following were incorrect answers:

Scanners Look for sequences of bit called signature that are typical malware programs. Active Monitors Active monitors interpret DOS and read-only memory (ROM) BIOS calls, looking for malware like actions. Active monitors can be problematic because they can not distinguish between a user request and a program or a malware request. As a result, users are asked to confirm actions, including formatting a disk or deleting a file or set of files.

Behavior Blocker Focus on detecting potential abnormal behavior such as writing to the boot sector or the master boot record, or making changes to executable files. Blockers can potentially detect malware at an early stage. Most hardware based anti-malware mechanism are based on this concept.
CISA review manual 2014 Page number 354 and 355

QUESTION 441

The drives of a tile server are backed up at a hot site. Which of the following is the BEST way to duplicate the files stored on the server for forensic analysis?

- A. Capture a bit-by-bit image of the file server's drives.
- B. Run forensic analysis software on the backup drive.
- C. Create a logical copy of the file server's drives.
- D. Replicate the server's volatile data to another drive.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 442

Which of the following statement is NOT true about Voice-Over IP (VoIP)?

- A. VoIP uses circuit switching technology
- B. Lower cost per call or even free calls, especially for long distance call
- C. Lower infrastructure cost
- D. VoIP is a technology where voice traffic is carried on top of existing data infrastructure

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The NOT is a keyword used in the question. You need to find out invalid statement about VoIP. VoIP uses packet switching and not circuit switching.

For your exam you should know below information about VoIP:

Voice-Over-IP

IP telephony, internet telephony, is the technology that makes it possible to have a voice conversation over the Internet or over any dedicated IP network instead of dedicated transmission lines. The protocol is used to carry the signal over the IP network are commonly referred as Voice-Over-IP (VoIP). VoIP is a technology where voice traffic is carried on top of existing data infrastructure. Sounds are digitalized into IP packets and transferred through the network layer before being decode back into the original voice.

VoIP allows the elimination of circuit switching and the associated waste of bandwidth. Instead, packet switching is used, where IP packets with voice data are sent over the network only when data needs to be sent.

It has advantages over traditional telephony:

Unlike traditional telephony, VoIP innovation progresses at market rates rather than at the rates of multilateral committee process of the International Telecommunication Union (ITU)

Lower cost per call or even free calls, especially for long distance call

Lower infrastructure costs. Once IP infrastructure is installed, no or little additional telephony infrastructure is needed

VoIP Security Issues

With the introduction of VoIP, the need for security is more important because it is needed to protect two assets the data and the voice.

Protecting the security of conversation is vital now.

In VoIP, packets are sent over the network from the user's computer or VoIP phone to similar equipment at other end. Packets may pass through several intermediate systems that are not under the control of the user's ISP. The current Internet architecture does not provide same physical wire security as phone line.

The main concern of VoIP solution is that while, in the case of traditional telephones, if data system is disrupted, then the different sites of the organization could still be reached via telephone. Thus a backup communication facility should be planned for if the availability of communication is vital to organization. Another issue might arise with the fact that IP telephones and their supporting equipment require the same care and maintenance as computer system do.

To enhance the protection of the telephone system and data traffic, the VoIP infrastructure should be segregated using Virtual Local Area Network (VLAN).

In many cases, session border controllers (SBCs) are utilized to provide security features for VoIP traffic similar to that provided by firewalls.

The following were incorrect answers:

Lower cost per call or even free calls, especially for long distance call - This is a valid statement about VoIP. In fact it is an advantage of VoIP.

Lower infrastructure cost This is a valid statement and advantage of using VoIP as compare to traditional telephony system.

VoIP is a technology where voice traffic is carried on top of existing data infrastructure This is also valid statement about VoIP.

CISA review manual 2014 Page number355

QUESTION 443

Private Branch Exchange(PBX) environment involves many security risks, one of which is the people both internal and external to an organization. Which of the following risks are NOT associated with Private Branch Exchange?

1. Theft of service
2. Disclosure of information
3. Data Modifications
4. Denial of service
5. Traffic Analysis

- A. 3 and 4
- B. 4 and 5
- C. 1-4
- D. They are ALL risks associated with PBX

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The NOT is a keyword used in the question. You need to find out the risks which are NOT associated with PBX. All the risk listed within the options are associated with PBX.

The threat of the PBX telephone system is many, depending on the goals of these attackers, and include:

Theft of service Toll fraud, probably the most common of motives for attacker.

Disclosure of Information Data disclosed without authorization, either by deliberate actionably accident. Examples includes eavesdropping on conversation and unauthorized access to routing and address data.

Data Modification Data altered in some meaningful way by recording, deleting or modifying it. For example,

an intruder may change billing information or modify system table to gain additional services.

Unauthorized access Actions that permit an unauthorized user to gain access to system resources or privileges.

Denial of service Actions that prevent the system from functioning in accordance with its intended purpose. A piece of equipment or entity may be rendered inoperable or forced to operate in a degraded state; operations that depend on timeliness may be delayed.

Traffic Analysis A form of passive attack in which an intruder observes information about calls and make inferences, e.g. from the source and destination number or frequency and length of messages. For example, an intruder observes a high volume of calls between a company's legal department and patent office, and conclude that a patent is being filed.

The following were incorrect answers:

All the risks presented in options are associated with PBX. So other options are not valid.
CISA review manual 2014 Page number 356

QUESTION 444

Which of the following is a sophisticated computer based switch that can be thought of as essentially a small in-house phone company for the organization?

- A. Private Branch Exchange
- B. Virtual Local Area Network
- C. Voice over IP
- D. Dial-up connection

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A Private Branch Exchange(PBX) is a sophisticated computer based switch that can be thought of as essentially a small in-house phone company for the organization that operates it. Protection of PBX is thus a height priority. Failure to secure PBX can result in exposing the organization to toll fraud, theft of proprietary or confidential information, loss of revenue or legal entanglements. PBX environment involves many security risks, presented by people both internal and external to an organization. The threat of the PBX telephone system is many, depending on the goals of these attackers, and include:

Theft of service Toll fraud, probably the most common of motives for attacker.

Disclosure of Information Data disclosed without authorization, either by deliberate actionably accident. Examples includes eavesdropping on conversation and unauthorized access to routing and address data.

Data Modification Data altered in some meaningful way by recording, deleting or modifying it. For example, an intruder may change billing information or modify system table to gain additional services.

Unauthorized access Actions that permit an unauthorized user to gain access to system resources or privileges.

Denial of service Actions that prevent the system from functioning in accordance with its intended purpose. A piece of equipment or entity may be rendered inoperable or forced to operate in a degraded state; operations that depend on timeliness may be delayed.

Traffic Analysis A form of passive attack in which an intruder observes information about calls and make inferences, e.g. from the source and destination number or frequency and length of messages. For example, an intruder observes a high volume of calls between a company's legal department and patent office, and conclude that a patent is being filed.

The following were incorrect answers:

Virtual Local Area Network A virtual local area network (VLAN) is a logical group of workstations, servers and network devices that appear to be on the same LAN despite their geographical distribution. A VLAN allows a network of computers and users to communicate in a simulated environment as if they exist in a single LAN and are sharing a single broadcast and multicast domain. VLANs are implemented to achieve scalability, security and ease of network management and can quickly adapt to change in network requirements and relocation of workstations and server nodes.

Voice over IP VoIP is a technology where voice traffic is carried on top of existing data infrastructure. Sounds are digitalized into IP packets and transferred through the network layer before being decode back into the original voice.

Dial-up connection Dial-up refers to an Internet connection that is established using a modem. The modem connects the computer to standard phone lines, which serve as the data transfer medium. When a user initiates a dial-up connection, the modem dials a phone number of an Internet Service Provider (ISP) that is designated to receive dial-up calls. The ISP then establishes the connection, which usually takes about ten seconds and is accompanied by several beeping an buzzing sounds.
CISA review manual 2014 Page number 356

QUESTION 445

Which of the following PBX feature provides the possibility to break into a busy line to inform another user of an important message?

- A. Account Codes
- B. Access Codes
- C. Override
- D. Tenanting

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Override feature of PBS provides for the possibility to break into a busy line to inform another user an important message.

For CISA exam you should know below mentioned PBS features and Risks

System Features

Description

Risk

Automatic Call distribution

Allows a PBX to be configured so that incoming calls are distributed to the next available agent or placed on- hold until one become available

Tapping and control of traffic

Call forwarding
Allow specifying an alternate number to which calls will be forwarded based on certain condition User tracking
Account codes

Used to:
Track calls made by certain people or for certain projects for appropriate billing Dial-In system access (user dials from outside and gain access to normal feature of the PBX) Changing the user class of service so a user can access a different set of features (i.e. the override feature)

Fraud, user tracking, non authorized features

Access Codes
Key for access to specific feature from the part of users with simple instruments, i.e. traditional analog phones.

Non-authorized features
Silent Monitoring
Silently monitors other calls
Eavesdropping
Conferencing

Allows for conversation among several users
Eavesdropping, by adding unwanted/unknown parties to a conference override(intrude)

Provides for the possibility to break into a busy line to inform another user an important message Eavesdropping
Auto-answer

Allows an instrument to automatically go when called usually gives an auditor or visible warning which can easily turned off

Gaining information not normally available, for various purpose

Tenanting
Limits system user access to only those users who belong to the same tenant group useful when one company leases out part of its building to other companies and tenants share an attendant, trunk lines,etc

Illegal usage, fraud, eavesdropping

Voice mail
Stores messages centrally and by using a password allows for retrieval from inside or outside lines. Disclosure or destruction of all messages of a user when that user's password is known or discovered by an intruder, disabling of the voice mail system and even the entire switch by lengthy messages or embedded codes, illegal access to external lines.

Privacy release
Supports shared extensions among several devices, ensuring that only one device at a time can use an extension. Privacy release disables the security by allowing devices to connect to an extension already in use.

Eavesdropping
No busy extension
Allows calls to an in-use extension to be added to a conference when that extension is on conference and already off-hook

Eavesdropping a conference in progress
Diagnostics
Allows for bypassing normal call restriction procedures. This kind of diagnostic is sometimes available from

any connected device. It is a separate feature, in addition to the normal maintenance terminal or attendant diagnostics

Fraud and illegal usage

Camp-on or call waiting
When activated, sends a visual audible warning to an off-hook instrument that is receiving another call. Another option of this feature is to conference with the camped-on or call waiting

Making the called individual a party to a conference without knowing it.

Dedicated connections
Connections made through the PBX without using the normal dialing sequences. It can be used to create hot- lines between devices i.e. one rings when the other goes off-hook. It is also used for data connections between devices and the central processing facility

Eavesdropping on a line

The following were incorrect answers:

Account Codes that are used to:
Track calls made by certain people or for certain projects for appropriate billing Dial-In system access (user dials from outside and gain access to normal feature of the PBX) Changing the user class of service so a user can access a different set of features (i.e. the override feature)

Access Codes Key for access to specific feature from the part of users with simple instruments, i.e. traditional analog phones.

Tenanting Limits system user access to only those users who belong to the same tenant group useful when one company leases out part of its building to other companies and tenants share an attendant, trunk lines,etc CISA review manual 2014 Page number 358

QUESTION 446

Which of the following PBX feature allows a PBX to be configured so that incoming calls are distributed to the next available agent or placed on-hold until one become available?

- A. Automatic Call distribution
- B. Call forwarding
- C. Tenanting
- D. Voice mail

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Automatic Call distribution allows a PBX to be configured so that incoming calls are distributed to the next available agent or placed on-hold until one become available

For your exam you should know below mentioned PBX features and Risks:

System Features

Description

Risk

Automatic Call distribution

Allows a PBX to be configured so that incoming calls are distributed to the next available agent or placed on- hold until one become available

Tapping and control of traffic

Call forwarding

Allow specifying an alternate number to which calls will be forwarded based on certain condition

User tracking

Account codes

Used to:

Track calls made by certain people or for certain projects for appropriate billing Dial-In system access (user dials from outside and gain access to normal feature of the PBX) Changing the user class of service so a user can access a different set of features (i.e. the override feature)

Fraud, user tracking, non authorized features

Access Codes

Key for access to specific feature from the part of users with simple instruments, i.e. traditional analog phones.

Non-authorized features

Silent Monitoring

Silently monitors other calls

Eavesdropping

Conferencing

Allows for conversation among several users

Eavesdropping, by adding unwanted/unknown parties to a conference override(intrude)

Provides for the possibility to break into a busy line to inform another user an important message

Eavesdropping

Auto-answer

Allows an instrument to automatically go when called usually gives an auditor or visible warning which can easily turned off

Gaining information not normally available, for various purpose

Tenancing

Limits system user access to only those users who belong to the same tenant group useful when one company leases out part of its building to other companies and tenants share an attendant, trunk lines,etc

Illegal usage, fraud, eavesdropping

Voice mail

Stores messages centrally and by using a password allows for retrieval from inside or outside lines.

Disclosure or destruction of all messages of a user when that user's password is known or discovered by an intruder, disabling of the voice mail system and even the entire switch by lengthy messages or embedded codes, illegal access to external lines.

Privacy release

Supports shared extensions among several devices, ensuring that only one device at a time can use an extension. Privacy release disables the security by allowing devices to connect to an extension already in use.

Eavesdropping

No busy extension

Allows calls to an in-use extension to be added to a conference when that extension is on conference and already off-hook

Eavesdropping a conference in progress

Diagnostics

Allows for bypassing normal call restriction procedures. This kind of diagnostic is sometimes available from any connected device. It is a separate feature, in addition to the normal maintenance terminal or attendant diagnostics

Fraud and illegal usage

Camp-on or call waiting

When activated, sends a visual audible warning to an off-hook instrument that is receiving another call. Another option of this feature is to conference with the camped-on or call waiting Making the called individual a party to a conference without knowing it.

Dedicated connections

Connections made through the PBX without using the normal dialing sequences. It can be used to create hot- lines between devices i.e. one rings when the other goes off-hook. It is also used for data connections between devices and the central processing facility

Eavesdropping on a line

The following were incorrect answers:

Call forwarding - Allow specifying an alternate number to which calls will be forwarded based on certain condition

Tenancing - Limits system user access to only those users who belong to the same tenant group useful when one company leases out part of its building to other companies and tenants share an attendant, trunk lines,etc Voice Mail - Stores messages centrally and by using a password allows for retrieval from inside or outside lines.

QUESTION 447

Which of the following PBX feature supports shared extensions among several devices, ensuring that only one device at a time can use an extension?

- A. Call forwarding
- B. Privacy release
- C. Tenanting
- D. Voice mail

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Privacy release supports shared extensions among several devices, ensuring that only one device at a time can use an extension.

For your exam you should know below mentioned PBX features and Risks:

System Features

Description

Risk

Automatic Call distribution

Allows a PBX to be configured so that incoming calls are distributed to the next available agent or placed on- hold until one become available

Tapping and control of traffic

Call forwarding

Allow specifying an alternate number to which calls will be forwarded based on certain condition

User tracking

Account codes

Used to:

Track calls made by certain people or for certain projects for appropriate billing Dial-In system access (user dials from outside and gain access to normal feature of the PBX) Changing the user class of service so a user can access a different set of features (i.e. the override feature)

Fraud, user tracking, non authorized features

Access Codes

Key for access to specific feature from the part of users with simple instruments, i.e. traditional analog phones.

Non-authorized features

Silent Monitoring

Silently monitors other calls

Eavesdropping

Conferencing

Allows for conversation among several users

Eavesdropping, by adding unwanted/unknown parties to a conference override(intrude)

Provides for the possibility to break into a busy line to inform another user an important message

Eavesdropping

Auto-answer

Allows an instrument to automatically go when called usually gives an auditor or visible warning which can easily turned off

Gaining information not normally available, for various purpose

Tenanting

Limits system user access to only those users who belong to the same tenant group useful when one company leases out part of its building to other companies and tenants share an attendant, trunk lines,etc

Illegal usage, fraud, eavesdropping

Voice mail

Stores messages centrally and by using a password allows for retrieval from inside or outside lines.

Disclosure or destruction of all messages of a user when that user's password is known or discovered by an intruder, disabling of the voice mail system and even the entire switch by lengthy messages or embedded codes, illegal access to external lines.

Privacy release

Supports shared extensions among several devices, ensuring that only one device at a time can use an extension. Privacy release disables the security by allowing devices to connect to an extension already in use.

Eavesdropping

No busy extension

Allows calls to an in-use extension to be added to a conference when that extension is on conference and already off-hook

Eavesdropping a conference in progress

Diagnostics

Allows for bypassing normal call restriction procedures. This kind of diagnostic is sometimes available from any connected device. It is a separate feature, in addition to the normal maintenance terminal or attendant diagnostics

Fraud and illegal usage

Camp-on or call waiting

When activated, sends a visual audible warning to an off-hook instrument that is receiving another call. Another option of this feature is to conference with the camped-on or call waiting

Making the called individual a party to a conference without knowing it.

Dedicated connections

Connections made through the PBX without using the normal dialing sequences. It can be used to create hot-lines between devices i.e. one rings when the other goes off-hook. It is also used for data connections between devices and the central processing facility

Eavesdropping on a line

The following were incorrect answers:

Call forwarding - Allow specifying an alternate number to which calls will be forwarded based on certain condition

Tenancing -Limits system user access to only those users who belong to the same tenant group useful when one company leases out part of its building to other companies and tenants share an attendant, trunk lines,etc

Voice Mail -Stores messages centrally and by using a password allows for retrieval from inside or outside lines.

CISA review manual 2014 Page number358

QUESTION 448

Which of the following option INCORRECTLY describes PBX feature?

- A. Voice mail -Stores messages centrally and by using a password allows for retrieval from inside or outside lines.
- B. Tenancing-Provides for the possibility to break into a busy line to inform another user an important message
- C. Automatic Call Distribution - Allows a PBX to be configured so that incoming calls are distributed to the next available agent or placed on-hold until one become available
- D. Diagnostics -Allows for bypassing normal call restriction procedures

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The word INCORRECTLY was the keyword used in the question. You need to find out the incorrectly described PBX feature from given options. The Tenancing feature is incorrectly described.

Tenancing limits system user access to only those users who belong to the same tenant group useful when one company leases out part of its building to other companies and tenants share an attendant, trunk lines,etc

For your exam you should know below mentioned PBX features and Risks:

System Features

Description

Risk

Automatic Call distribution

Allows a PBX to be configured so that incoming calls are distributed to the next available agent or placed on- hold until one become available

Tapping and control of traffic

Call forwarding

Allow specifying an alternate number to which calls will be forwarded based on certain condition

User tracking

Account codes

Used to:

Track calls made by certain people or for certain projects for appropriate billing

Dial-In system access (user dials from outside and gain access to normal feature of the PBX) Changing the user class of service so a user can access a different set of features (i.e. the override feature)

Fraud, user tracking, non authorized features

Access Codes

Key for access to specific feature from the part of users with simple instruments, i.e. traditional analog phones.

Non-authorized features

Silent Monitoring

Silently monitors other calls

Eavesdropping

Conferencing

Allows for conversation among several users

Eavesdropping, by adding unwanted/unknown parties to a conference override(intrude)

Provides for the possibility to break into a busy line to inform another user an important message

Eavesdropping

Auto-answer

Allows an instrument to automatically go when called usually gives an auditor or visible warning which can easily turned off

Gaining information not normally available, for various purpose

Tenancing

Limits system user access to only those users who belong to the same tenant group useful when one company leases out part of its building to other companies and tenants share an attendant, trunk lines,etc

Illegal usage, fraud, eavesdropping

Voice mail

Stores messages centrally and by using a password allows for retrieval from inside or outside lines.

Disclosure or destruction of all messages of a user when that user's password is known or discovered by an intruder, disabling of the voice mail system and even the entire switch by lengthy messages or embedded codes, illegal access to external lines.

Privacy release

Supports shared extensions among several devices, ensuring that only one device at a time can use an extension. Privacy release disables the security by allowing devices to connect to an extension already in use.

Eavesdropping

No busy extension

Allows calls to an in-use extension to be added to a conference when that extension is on conference and already off-hook

Eavesdropping a conference in progress

Diagnostics

Allows for bypassing normal call restriction procedures. This kind of diagnostic is sometimes available from any connected device. It is a separate feature, in addition to the normal maintenance terminal or attendant diagnostics

Fraud and illegal usage

Camp-on or call waiting

When activated, sends a visual audible warning to an off-hook instrument that is receiving another call. Another option of this feature is to conference with the camped-on or call waiting

Making the called individual a party to a conference without knowing it.

Dedicated connections

Connections made through the PBX without using the normal dialing sequences. It can be used to create hot-lines between devices i.e. one rings when the other goes off-hook. It is also used for data connections between devices and the central processing facility

Eavesdropping on a line

The following were incorrect answers:

The other options presented correctly describes PBX features thus not the right choice.

CISA review manual 2014 Page number 358

QUESTION 449

Which of the following technique is NOT used by a preacher against a Private Branch Exchange (PBX)?

- A. Eavesdropping
- B. Illegal call forwarding
- C. Forwarding a user to an unused or disabled number
- D. SYN Flood

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The word NOT the keyword used in the question. You need to find out the technique which preacher do not use to exploit PBX.

SYN Flood -Sends a flood of TCP/SYN packets with forged sender address, causing half-open connections and saturates available connection capacity on the target machine.

For CISA Exam you should know below mentioned techniques used by preacher for illegal purpose of PBX.

Eavesdropping on conversation, without the other parties being aware of it Eavesdropping on conference call

Illegal forwarding calls from specific equipment to remote numbers Forwarding a user to an unused or disabled number, thereby making it unreachable by external calls.

The following were incorrect answers:

The other options presented correctly describes the techniques used preacher for illegal purpose of PBX.

CISA review manual 2014 Page number 357

QUESTION 450

Who is primarily responsible for storing and safeguarding the data?

- A. Data Owner
- B. Data User
- C. Data Steward
- D. Security Administrator

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data Steward or data custodian is responsible for storing and safeguarding the data, and include IS personnel such as system analyst and computer operators.

For CISA exam you should know below roles in an organization

Data Owners These peoples are generally managers and directors responsible for using information for running and controlling the business. Their security responsibilities include authorizing access, ensuring that access rules are updated when personnel changes occur, and regularly review access rule for the data for which they are responsible.

Data Custodian or Data Steward These people are responsible for storing and safeguarding the data, and include IS personnel such as system analysis and computer operators.

Security Administrator -Security administrator is responsible for providing adequate physical and logical security for IS programs, data and equipment.

Data Users Data users, including internal and external user community, are the actual user of computerized data. Their level of access into the computer should be authorized by data owners, and restricted and monitor by security administrator.

The following were incorrect answers:

Data Owner- These peoples are generally managers and directors responsible for using information for running and controlling the business.

Data Users Data users, including internal and external user community, are the actual user of computerized data.

Security Administrator - Security administrator is responsible for providing adequate and logical security for IS programs, data and equipment.
CISA review manual 2014 Page number 361

QUESTION 451

Who is responsible for providing adequate physical and logical security for IS program, data and equipment?

- A. Data Owner
- B. Data User
- C. Data Custodian
- D. Security Administrator

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Security administrator are responsible for providing adequate physical and logical security for IS programs, data and equipment.

For CISA exam you should know below roles in an organization

Data Owners These peoples are generally managers and directors responsible for using information for running and controlling the business. Their security responsibilities include authorizing access, ensuring that access rules are updated when personnel changes occur, and regularly review access rule for the data for which they are responsible.

Data Custodian or Data Steward These people are responsible for storing and safeguarding the data, and include IS personnel such as system analysis and computer operators.

Security Administrator -Security administrator is responsible for providing adequate physical and logical security for IS programs, data and equipment.

Data Users Data users, including internal and external user community, are the actual user of computerized data. Their level of access into the computer should be authorized by data owners, and restricted and monitor by security administrator.

The following were incorrect answers:

Data Owner- These peoples are generally managers and directors responsible for using information for running and controlling the business.

Data Users Data users, including internal and external user community, are the actual user of computerized data.

Data custodian is responsible for storing and safeguarding the data, and include IS personnel such as system analyst and computer operators.
CISA review manual 2014 Page number 361

QUESTION 452

Who is responsible for restricting and monitoring access of a data user?

- A. Data Owner
- B. Data User
- C. Data Custodian
- D. Security Administrator

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Security administrator are responsible for providing adequate and logical security for IS programs, data and equipment.

For CISA exam you should know below roles in an organization

Data Owners These peoples are generally managers and directors responsible for using information for running and controlling the business. Their security responsibilities include authorizing access, ensuring that access rules are updated when personnel changes occur, and regularly review access rule for the data for which they are responsible.

Data Custodian or Data Steward These people are responsible for storing and safeguarding the data, and include IS personnel such as system analysis and computer operators.

Security Administrator-Security administrator are responsible for providing adequate physical and logical security for IS programs, data and equipment.

Data Users Data users, including internal and external user community, are the actual user of computerized data. Their level of access into the computer should be authorized by data owners, and restricted and monitor by security administrator.

The following were incorrect answers:

Data Owner - These peoples are generally managers and directors responsible for using information for running and controlling the business.

Data Users Data users, including internal and external user community, are the actual user of computerized data.

Data custodian is responsible for storing and safeguarding the data, and include IS personnel such as system analyst and computer operators.
CISA review manual 2014 Page number 361

QUESTION 453

Who is responsible for authorizing access level of a data user?

- A. Data Owner
- B. Data User
- C. Data Custodian
- D. Security Administrator

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data owners are responsible for authorizing access level of a data user. These people are generally managers and directors responsible for using information for running and controlling the business. Their security responsibilities include authorizing access, ensuring that access rules are updated when personnel changes occur, and regularly review access rule for the data for which they are responsible.

For your exam you should know below roles in an organization

Data Owners Data Owners are generally managers and directors responsible for using information for running and controlling the business. Their security responsibilities include authorizing access, ensuring that access rules are updated when personnel changes occur, and regularly review access rule for the data for which they are responsible.

Data Custodian or Data Steward are responsible for storing and safeguarding the data, and include IS personnel such as system analysis and computer operators.

Security Administrator -Security administrator is responsible for providing adequate physical and logical security for IS programs, data and equipment.

Data Users Data users, including internal and external user community, are the actual user of computerized data. Their level of access into the computer should be authorized by data owners, and restricted and monitor by security administrator.

The following were incorrect answers:

Security Administrator -Security administrator is responsible for providing adequate and logical security for IS programs, data and equipment.

Data Users Data users, including internal and external user community, are the actual user of computerized data.

Data custodian is responsible for storing and safeguarding the data, and include IS personnel such as system analyst and computer operators.

CISA review manual 2014 Page number 361

QUESTION 454

During Involuntary termination of an employee, which of the following is the MOST important step to be considered?

- A. Get a written NDA agreement from an employee
- B. Terminate all physical and logical access
- C. Provide compensation in lieu of notice period
- D. Do not communicate to the respective employee about the termination

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

For CISA exam you should know below information about Terminated Employee Access

Termination of employment can occur in the following circumstances:

On the request of the employee (Voluntary resignation from service) Scheduled (On retirement or completion of contract)

Involuntary (forced by management in special circumstances)

In case of an involuntary termination of employment, the logical and physical access rights of employees to the IT infrastructure should either be withdrawn completely or highly restricted as early as possible, before the employee become aware of termination or its likelihood.

This ensures that terminated employees cannot continue to access potentially confidential or damaging information from the IT resources or perform any action that would result in damage of any kind of IT infrastructure, applications and data. Similar procedure in place to terminate access for third parties upon terminating their activities with the organization.

When it is necessary for employee to continue to have accesses, such access must be monitored carefully and continuously and should take place with senior management's knowledge and authorization.

In case of a voluntary or scheduled termination of employment, it is management's prerogative to decide whether access is restricted or withdrawn. This depends on:

The specific circumstances associated with each case

The sensitivity of employee's access to the IT infrastructure and resources The requirement of the organization's information security policies, standards and procedure.

The following were incorrect answers:

The other options presented are incorrectly describes about involuntary termination.

CISA review manual 2014 Page number 361 and 362

QUESTION 455

While evaluating logical access control the IS auditor should follow all of the steps mentioned below EXCEPT one?

1. Obtain general understanding of security risk facing information processing, through a review of relevant documentation, inquiry and observation,etc
2. Document and evaluate controls over potential access paths into the system to assess their adequacy, efficiency and effectiveness
3. Test Control over access paths to determine whether they are functioning and effective by applying appropriate audit technique
4. Evaluate the access control environment to determine if the control objective is achieved by analyzing test

result and other audit evidence

5. Evaluate the security environment to assess its adequacy by reviewing written policies, observing practices and procedures, and comparing them with appropriate security standard or practice and procedures used by other organization.

6. Evaluate and deploy technical controls to mitigate all identified risks during audit.

- A. 2
- B. 3

- C. 1
- D. 6

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The word EXCEPT is the keyword used in the question. You need find out the item an IS auditor should not perform while evaluating logical access control. It is not an IT auditor's responsibility to evaluate and deploy technical controls to mitigate all identified risks during audit. For CISA exam you should know below information about auditing logical access:

Obtain general understanding of security risk facing information processing, through a review of relevant documentation, inquiry and observation, etc

Document and evaluate controls over potential access paths into the system to assess their adequacy, efficiency and effectiveness

Test Control over access paths to determine whether they are functioning and effective by applying appropriate audit technique

Evaluate the access control environment to determine if the control objective are achieved by analyzing test result and other audit evidence

Evaluate the security environment to assess its adequacy by reviewing written policies, observing practices and procedures, and comparing them with appropriate security standard or practice and procedures used by other organization.

The following were incorrect answers:

The other options presented are valid choices which IS auditor needs to follow while evaluating logical access control.

CISA review manual 2014 Page number 362

QUESTION 456

Identify the correct sequence which needs to be followed as a chain of event in regards to evidence handling in computer forensics?

- A. Identify, Analyze, preserve and Present
- B. Analyze, Identify, preserve and present
- C. Preserve, Identify, Analyze and Present
- D. Identify, Preserve, Analyze and Present

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

There are 4 major considerations in the chain of event in regards to evidence in computer forensics:

Identify -Refers to identification of information that is available and might form evidence of an accident

Preserve -Refers to the practice of retrieving identified information and preserving it as evidence. The practice generally includes the imaging of original media in presence of an independent third party. The process also requires being able to document chain-of-custody so that it can be established in a court law.

Analyze Involves extracting, processing and interpreting the evidence. Extracted data could be unintelligible binary data after it has been processed and converted into human readable format. Interpreting the data requires an in-depth knowledge of how different pieces of evidences may fit together. The analysis should be performed using an image of media and not the original.

Present -Involves a presentation of the various audiences such as management, attorneys, court, etc. Acceptance of evidence depends upon the manner of presentation, qualification of the presenter, and credibility of the process used to preserve and analyze the evidence.

The following were incorrect answers:

The other options presented are not a valid sequence which needs to be followed in the chain of events in regards to evidence in computer forensics.

CISA review manual 2014 Page number 367

QUESTION 457

In computer forensics, which of the following is the process that allows bit-for-bit copy of a data to avoid damage of original data or information when multiple analysis may be performed?

- A. Imaging
- B. Extraction
- C. Data Protection
- D. Data Acquisition

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Imaging is the process that allows one to obtain a bit-for bit copy of a data to avoid damage to the original data or information when multiple analysis may be performed. The imaging process is made to obtain residual data, such as deleted files, fragments of deleted files and other information present, from the disk for analysis. This is possible because imaging duplicates the disk surface, sector by sector.

For CISA exam you should know below mentioned key elements of computer forensics during audit planning.

Data Protection -To prevent sought-after information from being altered, all measures must be in place. It is important to establish specific protocol to inform appropriate parties that electronic evidence will be sought and not destroy it by any means.

Data Acquisition All information and data required should transferred into a controlled location; this includes all types of electronic media such as fixed disk drives and removable media. Each device must be checked to ensure that it is write protected. This may be achieved by using device known as write blocker.

Imaging -The Imaging is a process that allows one to obtain bit-for bit copy of a data to avoid damage of original data or information when multiple analyses may be performed. The imaging process is made to obtain

residual data, such as deleted files, fragments of deleted files and other information present, from the disk for analysis. This is possible because imaging duplicates the disk surface, sector by sector.

Extraction - This process consists of identification and selection of data from the imaged data set. This process should include standards of quality, integrity and reliability. The extraction process includes software used and media where an image was made. The extraction process could include different sources such as system logs, firewall logs, audit trails and network management information.

Interrogation -Integration is used to obtain prior indicators or relationships, including telephone numbers, IP addresses, and names of individuals from extracted data.

Investigation/ Normalization -This process converts the information extracted to a format that can be understood by investigator. It includes conversion of hexadecimal or binary data into readable characters or a format suitable for data analysis tool.

Reporting- The information obtained from computer forensic has limited value when it is not collected and reported in proper way. When an IS auditor writes report, he/she must include why the system was reviewed, how the computer data were reviewed and what conclusion were made from analysis. The report should achieve the following goals

Accurately describes the details of an incident.

Be understandable to decision makers.

Be able to withstand a barrage of legal security

Be unambiguous and not open to misinterpretation.

Be easily referenced

Contains all information required to explain conclusions reached Offer valid conclusions, opinions or recommendations when needed Be created in timely manner.

The following were incorrect answers:

Extraction - This process consists of identification and selection of data from the imaged data set. This process should include standards of quality, integrity and reliability.

Data Protection -To prevent sought-after information from being altered, all measures must be in place. It is important to establish specific protocol to inform appropriate parties that electronic evidence will be sought and not destroy it by any means.

Data Acquisition All information and data required should transferred into a controlled location; this includes all types of electronic media such as fixed disk drives and removable media. Each device must be checked to ensure that it is write protected. This may be achieved by using device known as write blocker.
CISA review manual 2014 Page number367 and 368

QUESTION 458

In computer forensic which of the following describe the process that converts the information extracted into a format that can be understood by investigator?

- A. Investigation
- B. Interrogation
- C. Reporting
- D. Extraction

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Investigation is the process that converts the information extracted to a format that can be understood by investigator. It includes conversion of hexadecimal or binary data into readable characters or a format suitable for data analysis tool.

For CISA exam you should know below mentioned key elements of computer forensics during audit planning.

Data Protection -To prevent sought-after information from being altered, all measures must be in place. It is important to establish specific protocol to inform appropriate parties that electronic evidence will be sought and not destroy it by any means.

Data Acquisition All information and data required should transferred into a controlled location; this includes all types of electronic media such as fixed disk drives and removable media. Each device must be checked to ensure that it is write protected. This may be achieved by using device known as write blocker.

Imaging -The Imaging is a process that allows one to obtain bit-for bit copy of a data to avoid damage of original data or information when multiple analyses may be performed. The imaging process is made to obtain residual data, such as deleted files, fragments of deleted files and other information present, from the disk for analysis. This is possible because imaging duplicates the disk surface, sector by sector. Extraction - This process consists of identification and selection of data from the imaged data set. This process should include standards of quality, integrity and reliability. The extraction process includes software used and media where an image was made. The extraction process could include different sources such as system logs, firewall logs, audit trails and network management information.

Interrogation -Integration is used to obtain prior indicators or relationships, including telephone numbers, IP addresses, and names of individuals from extracted data.

Investigation/ Normalization -This process converts the information extracted to a format that can be understood by investigator. It includes conversion of hexadecimal or binary data into readable characters or a format suitable for data analysis tool.

Reporting- The information obtained from computer forensic has limited value when it is not collected and reported in proper way. When an IS auditor writes report, he/she must include why the system was reviewed, how the computer data were reviewed and what conclusion were made from analysis. The report should achieve the following goals

Accurately describes the details of an incident.

Be understandable to decision makers.

Be able to withstand a barrage of legal security

Be unambiguous and not open to misinterpretation.

Be easily referenced

Contains all information required to explain conclusions reached Offer valid conclusions, opinions or recommendations when needed Be created in timely manner.

The following were incorrect answers:

Interrogation -Integration is used to obtain prior indicators or relationships, including telephone numbers, IP addresses, and names of individuals from extracted data.

Extraction - This process consists of identification and selection of data from the imaged data set. This process should include standards of quality, integrity and reliability.

Reporting -The information obtained from computer forensic has limited value when it is not collected and reported in proper way. When an IS auditor writes report, he/she must include why the system was reviewed, how the computer data were reviewed and what conclusion were made from analysis.
CISA review manual 2014 Page number 367 and 368

QUESTION 459

Which of the following process consist of identification and selection of data from the imaged data set in computer forensics?

- A. Investigation

- B. Interrogation
- C. Reporting
- D. Extraction

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Extraction is the process of identification and selection of data from the imaged data set. This process should include standards of quality, integrity and reliability. The extraction process includes software used and media where an image was made. The extraction process could include different sources such as system logs, firewall logs, audit trails and network management information.

For CISA exam you should know below mentioned key elements of computer forensics during audit planning.

Data Protection -To prevent sought-after information from being altered, all measures must be in place. It is important to establish specific protocol to inform appropriate parties that electronic evidence will be sought and not destroy it by any means.

Data Acquisition All information and data required should transferred into a controlled location; this includes all types of electronic media such as fixed disk drives and removable media. Each device must be checked to ensure that it is write protected. This may be achieved by using device known as write blocker.

Imaging -The Imaging is a process that allows one to obtain bit-for bit copy of a data to avoid damage of original data or information when multiple analyses may be performed. The imaging process is made to obtain residual data, such as deleted files, fragments of deleted files and other information present, from the disk for analysis. This is possible because imaging duplicates the disk surface, sector by sector.

Extraction - This process consists of identification and selection of data from the imaged data set. This process should include standards of quality, integrity and reliability. The extraction process includes software used and media where an image was made. The extraction process could include different sources such as system logs, firewall logs, audit trails and network management information.

Interrogation -Integration is used to obtain prior indicators or relationships, including telephone numbers, IP addresses, and names of individuals from extracted data.

Investigation/ Normalization -This process converts the information extracted to a format that can be understood by investigator. It includes conversion of hexadecimal or binary data into readable characters or a format suitable for data analysis tool.

Reporting- The information obtained from computer forensic has limited value when it is not collected and reported in proper way. When an IS auditor writes report, he/she must include why the system was reviewed, how the computer data were reviewed and what conclusion were made from analysis. The report should achieve the following goals

Accurately describes the details of an incident.

Be understandable to decision makers.

Be able to withstand a barrage of legal security

Be unambiguous and not open to misinterpretation.

Be easily referenced

Contains all information required to explain conclusions reached Offer valid conclusions, opinions or recommendations when needed Be created in timely manner.

The following were incorrect answers:

Investigation/ Normalization -This process converts the information extracted to a format that can be understood by investigator. It includes conversion of hexadecimal or binary data into readable characters or a format suitable for data analysis tool.

Interrogation -Integration is used to obtain prior indicators or relationships, including telephone numbers, IP addresses, and names of individuals from extracted data.

Reporting -The information obtained from computer forensic has limited value when it is not collected and reported in proper way. When an IS auditor writes report, he/she must include why the system was reviewed, how the computer data were reviewed and what conclusion were made from analysis.

CISA review manual 2014 Page number 367 and 368

QUESTION 460

There are several types of penetration tests depending upon the scope, objective and nature of a test. Which of the following describes a penetration test where you attack and attempt to circumvent the controls of the targeted network from the outside, usually the Internet?

- A. External Testing
- B. Internal Testing
- C. Blind Testing
- D. Targeted Testing

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

External testing refers to attack and control circumvention attempts on a target's network perimeter from outside the target's system, usually the Internet.

For the CISA exam you should know penetration test types listed below:

External Testing -Refers to attack and control circumvention attempts on a target's network perimeter from outside the target's system, usually the Internet

Internal Testing Refers to attack and control circumvention attempt on target from within the perimeter. The objective is to identify what would occur if the external perimeter was successfully compromised and/or an authorized user from within the network wanted to compromise security of a specific resource on a network.

Blind Testing -Refers to the condition of testing when the penetration tester is provided with limited or no knowledge of the target's information systems. Such testing is expensive, since penetration tester have to research the target and profile it based on publicly available information.

Double Blind Testing -It is an extension of blind testing, since the administrator and security staff at the target are also not aware of test. Such a testing can effectively evaluate the incident handling and response capability of the target and how well managed the environment is.

Targeted Testing Refers to attack and control circumvention attempts on the target, while both the target's IT team and penetration tester are aware of the testing activities. Penetration testers are provided with information related to target and network design. Additionally, they are also provided with a limited privilege user account to be used as a starting point to identify privilege escalation possibilities in the system.

The following were incorrect answers:

Internal Testing Refers to attack and control circumvention attempt on target from within the perimeter. The objective is to identify what would occur if the external perimeter was successfully compromised and/or an authorized user from within the network wanted to compromise security of a specific resource on a network.

Blind Testing -Refers to the condition of testing when the penetration tester is provided with limited or no knowledge of the target's information systems. Such a testing is expensive, since penetration tester have to research the target and profile it based on publicly available information.

Targeted Testing Refers to attack and control circumvention attempts on the target, while both the target's IT team and penetration tester are aware of the testing activities. Penetration testers are provided with information related to target and network design. Additionally, they are also provided with a limited privilege user account to be used as a starting point to identify privilege escalation possibilities in the system.

CISA review manual 2014 Page number 369

QUESTION 461

Which of the following is penetration test where the penetration tester is provided with limited or no knowledge of the target's information systems?

- A. External Testing
- B. Internal Testing
- C. Blind Testing
- D. Targeted Testing

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Blind Testing refers to the condition of testing when the penetration tester is provided with limited or no knowledge of the target. Such a testing is expensive, since the penetration tester has to research the target and profile it based on publicly available information.

For your exam you should know below mentioned penetration types

External Testing -Refers to attack and control circumvention attempts on a target's network perimeter from outside the target's system is usually the Internet

Internal Testing Refers to attack and control circumvention attempt on target from within the perimeter. The objective is to identify what would occur if the external perimeter was successfully compromised and/or an authorized user from within the network wanted to compromise security of a specific resource on a network.

Blind Testing -Refers to the condition of testing when the penetration tester is provided with limited or no knowledge of the target's information systems. Such a testing is expensive, since penetration tester have to research the target and profile it based on publicly available information.

Double Blind Testing -It is an extension of blind testing, since the administrator and security staff at the target are also not aware of test. Such a testing can effectively evaluate the incident handling and response

capability of the target.

Targeted Testing Refers to attack and control circumvention attempts on the target, while both the target's IT team and penetration tester are aware of the testing activities. Penetration testers are provided with information related to target and network design. Additionally, they are also provided with a limited privilege user account to be used as a starting point to identify privilege escalation possibilities in the system.

The following were incorrect answers:

External Testing -Refers to attack and control circumvention attempts on a target's network perimeter from outside the target's system is usually the Internet

Internal Testing Refers to attack and control circumvention attempt on target from within the perimeter. The objective is to identify what would occur if the external perimeter was successfully compromised and/or an authorized user from within the network wanted to compromise security of a specific resource on a network.

Targeted Testing Refers to attack and control circumvention attempts on the target, while both the target's IT team and penetration tester are aware of the testing activities. Penetration testers are provided with information related to target and network design. Additionally, they are also provided with a limited privilege user account to be used as a starting point to identify privilege escalation possibilities in the system.

CISA review manual 2014 Page number 369

QUESTION 462

Which of the following is an environmental issue caused by electric storms or noisy electric equipment and may also cause computer system to hang or crash?

- A. Sag
- B. Blackout
- C. Brownout
- D. EMI

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The electromagnetic interference (EMI) caused by electrical storms or noisy electrical equipments. The interference may cause computer system to hang or crash as well as damages similar to those caused by sags, spike and surges.

Because Unshielded Twisted Pair cables does not have shielding like shielded twisted-pair cables, UTP is susceptible to interference from external electrical sources, which could reduce the integrity of the signal. Also, to intercept transmitted data, an intruder can install a tap on the cable or monitor the radiation from the wire. Thus, UTP may not be a good choice when transmitting very sensitive data or when installed in an environment with much electromagnetic interference (EMI) or radio frequency interference (RFI). Despite its drawbacks, UTP is the most common cable type. UTP is inexpensive, can be easily bent during installation, and, in most cases, the risk from the above drawbacks is not enough to justify more expensive cables.

For your exam you should know below information about power failure

Total Failure (Blackout) A complete loss of electric power, which may span from a single building to an entire geographical area and is often caused by weather conditions or inability of an electric utility company to meet user demands

Severely reduced voltage (brownout) The failure of an electric utility company to supply power within

acceptable range. Such a failure places a strain on electronic equipment and may limit their operational life or even cause permanent damage.

Sags, spike and surge Temporary and rapid decreases (sag) or increases (spike and surges) in a voltage levels. These anomalies can cause loss of data, data corruption, network transmission errors or physical damage to hardware devices.

Electromagnetic interference (EMI) - The electromagnetic interference (EMI) caused by electrical storms or noisy electrical equipments. The interference may cause computer system to hang or crash as well as damages similar to those caused by sags, spike and surges.

The following were incorrect answers:

Sag Temporarily rapid decrease in a voltage.

Total Failure (Blackout) A complete loss of electric power, which may span from a single building to an entire geographical are and is often caused by weather conditions or inability of an electric utility company to meet user demands

Severely reduced voltage (brownout) The failure of an electric utility company to supply power within acceptable range. Such a failure places a strain on electronic equipment and may limit their operational life or even cause permanent damage.

CISA review manual 2014 Page number372

and

Hernandez CISSP, Steven (2012-12-21). Official (ISC)2 Guide to the CISSP CBK, Third Edition ((ISC)2 Press) (Kindle Locations 6507-6512). Acerbic Publications. Kindle Edition.

QUESTION 463

Which of the following term describes a failure of an electric utility company to supply power within acceptable range?

- A. Sag
- B. Blackout
- C. Brownout
- D. EMI

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The failure of an electric utility company to supply power within acceptable range. Such a failure places a strain on electronic equipment and may limit their operational life or even cause permanent damage.

For CISA exam you should know below information about power failure

Total Failure (Blackout) A complete loss of electric power, which may span from a single building to an entire geographical are and is often caused by weather conditions or inability of an electric utility company to meet user demands

Severely reduced voltage (brownout) The failure of an electric utility company to supply power within acceptable range. Such a failure places a strain on electronic equipment and may limit their operational life or even cause permanent damage.

Sags, spike and surge Temporary and rapid decreases (sag) or increases (spike and surges) in a voltage levels. These anomalies can cause loss of data, data corruption, network transmission errors or physical damage to hardware devices.

Electromagnetic interference (EMI) - The electromagnetic interference (EMI) caused by electrical storms or noisy electrical equipments. The interference may cause computer system to hang or crash as well as damages similar to those caused by sags, spike and surges.

The following were incorrect answers:

Sag Temporarily rapid decrease in a voltage.

Total Failure (Blackout) A complete loss of electric power, which may span from a single building to an entire geographical are and is often caused by weather conditions or inability of an electric utility company to meet user demands

Severely reduced voltage (brownout) The failure of an electric utility company to supply power within acceptable range. Such a failure places a strain on electronic equipment and may limit their operational life or even cause permanent damage.

CISA review manual 2014 Page number372

QUESTION 464

Which of the following statement is NOT true about smoke detector?

- A. The Smoke detectors should be above and below the ceiling tiles throughout the facilities and below the raised in the computer room floor
- B. The smoke detector should produce an audible alarm when activated and be linked to a monitored station
- C. The location of the smoke detector should be marked on the tiling for easy identification and access
- D. Smoke detector should replace fire suppression system

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The word NOT is the keyword used in the question. You need to find out a statement which is not applicable to smoke detector. Smoke detector should supplement, not replace, fire suppression system.

For CISA exam you should know below information about smoke detector.

The Smoke detectors should be above and below the ceiling tiles throughout the facilities and below the raised computer room floor.

The smoke detector should produce an audible alarm when activated be linked to a monitored station The location of the smoke detector should be marked on the tiling for easy identification and access. Smoke detector should supplement, not replace, fire suppression system

The following were incorrect answers:

The other presented options are valid statement about smoke detector.

CISA review manual 2014 Page number373

QUESTION 465

Which of the following statement correctly describes the difference between total flooding and local application extinguishing agent?

- A. The local application design contain physical barrier enclosing the fire space where as physical barrier is not present in total flooding extinguisher
- B. The total flooding design contain physical barrier enclosing the fire space where as physical barrier is not present in local application design extinguisher
- C. The physical barrier enclosing fire space is not present in total flooding and local application extinguisher agent
- D. The physical barrier enclosing fire space is present in total flooding and local application extinguisher agent

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

For CISA exam you should know below information about Fire Suppression Systems

Fire Suppression System

This system is designed to automatically activate immediately after detection of heat, typically generated by fire. Like smoke detectors, the system will produce an audible alarm when activated and be linked to a central guard station that is regularly monitored. The system should also be inspected and tested annually. Testing interval should comply with industry and insurance standard and guideline.

Broadly speaking there are two methods for applying an extinguisher agent: total flooding and local application.

Total Flooding - System working under total flooding application apply an extinguishing agent to a three dimensional enclosed space in order to achieve a concentration of the agent (volume percentage of agent in air) adequate to extinguish the fire. These type of system may be operated automatically by detection and related controls or manually by the operation of a system actuator.

Local Application - System working under a local application principle apply an extinguishing agent directly onto a fire (usually a two dimensional area) or into a three dimensional region immediately surrounding the substance or object on a fire. The main difference between local application and total flooding design is the absence of physical barrier enclosing the fire space in the local application design.

The medium of fire suppression varies but usually one of the following:

Water based systems are typically referred to as sprinkler system. These systems are effective but are also unpopular because they damage equipment and property. The system can be dry-pipe or charged (water is always in system piping). A charged system is more reliable but has the disadvantage of exposing the facility to expensive water damage if the pipe leak or break.

Dry-pipe sprinkling system do not have water in the pipe until an electronic fire alarm activates the water to send water into system. This is opposed to fully charged water pipe system. Dry-pipe system has the advantage that any failure in the pipe will not result in water leaking into sensitive equipment from above. Since water and electricity do not mix these systems must be combined with an automatic switch to shut down the electric supply to the area protected.

Halon system releases pressurize halos gases that removes oxygen from air, thus starving the fire. Halon was popular because it is an inert gas and does not damage and does not damage equipment like water does. Because halos adversely affect the ozone layer, it was banned in Montreal (Canada) protocol 1987, which stopped Halon production as of 1 January 1994. As a banned gas, all Halon installation are now required by international agreement to be removed. The Halon substitute is FM-200, which is the most effective alternative.

FM-220TM: Also called heptafluoropropane, HFC-227 or HFC-227ea(ISO Name)is a colorless odorless gaseous fire suppression agent. It is commonly used as a gaseous fire suppression agent.

Aragonite is the brand name for a mixture of 50% argon and 50% nitrogen. It is an inert gas used in gaseous fire suppression systems for extinguishing fires where damage to equipment is to be avoided. Although argon is a nontoxic, it does not satisfy the body's need for oxygen and is simple asphyxiate.

CO2 system releases pressurized carbon dioxide gas into the area protected to replace the oxygen required for combustion. Unlike halos and its later replacement, however, CO2 is unable to sustain human life. Therefore, in most of countries it is illegal to for such a system to be set to automatic release if any human may be in the area. Because of this, these systems are usually discharged manually, introducing an additional delay in combating fire.

The following were incorrect answers:

The other presented options do not describe valid difference between total flooding and local application extinguishing agent.

CISA review manual 2014 Page number 373 and 374

QUESTION 466

Which of the following type of lock uses a numeric keypad or dial to gain entry?

- A. Bolting door locks
- B. Cipher lock
- C. Electronic door lock
- D. Biometric door lock

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The combination door lock or cipher lock uses a numeric key pad, push button, or dial to gain entry, it is often seen at airport gate entry doors and smaller server rooms. The combination should be changed at regular interval or whenever an employee with access is transferred, fired or subject to disciplinary action. This reduces risk of the combination being known by unauthorized people.

A cipher lock, is controlled by a mechanical key pad, typically 5 to 10 digits that when pushed in the right combination the lock will releases and allows entry. The drawback is someone looking over a shoulder can see the combination. However, an electric version of the cipher lock is in production in which a display screen will automatically move the numbers around, so if someone is trying to watch the movement on the screen they will not be able to identify the number indicated unless they are standing directly behind the victim.

Remember locking devices are only as good as the wall or door that they are mounted in and if the frame of the door or the door itself can be easily destroyed then the lock will not be effective. A lock will eventually be defeated and its primary purpose is to delay the attacker.

For your exam you should know below types of lock

Bolting door lock These locks required the traditional metal key to gain entry. The key should be stamped "do not duplicate" and should be stored and issued under strict management control.

Biometric door lock An individual's unique physical attribute such as voice, retina, fingerprint, hand geometry or signature, activate these locks. This system is used in instances when sensitive facilities must be protected such as in the military.

Electronic door lock This system uses a magnetic or embedded chip based plastic card key or token entered

into a sensor reader to gain access. A special code internally stored in the card or token is read by sensor device that then activates the door locking mechanism.

The following were incorrect answers:

Bolting door lock These locks required the traditional metal key to gain entry. The key should be stamped "do not duplicate" and should be stored and issued under strict management control.

Biometric door lock An individual's unique body features such as voice, retina, fingerprint, hand geometry or signature, activate these locks. This system is used in instances when extremely sensitive facilities must be protected such as in the military.

Electronic door lock This system uses a magnetic or embedded chip based plastic card key or token entered into a sensor reader to gain access. A special code internally stored in the card or token is read by sensor device that then activates the door locking mechanism.

CISA review manual 2014 Page number 376

and

Hernandez CISSP, Steven (2012-12-21). Official (ISC)2 Guide to the CISSP CBK, Third Edition ((ISC)2 Press) (Kindle Locations 25144-25150). Acerbic Publications. Kindle Edition.

QUESTION 467

Which of the following type of lock uses a magnetic or embedded chip based plastic card key or token entered into a sensor/reader to gain access?

- A. Bolting door locks
- B. Combination door lock
- C. Electronic door lock
- D. Biometric door lock

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Electronic door lock uses a magnetic or embedded chip based plastic card key or token entered into a sensor reader to gain access. A special code internally stored in the card or token is read by sensor device that then activates the door locking mechanism.

For CISA exam you should know below types of lock

Bolting door lock These locks required the traditional metal key to gain entry. The key should be stamped "do not duplicate" and should be stored and issued under strict management control.

Biometric door lock An individual's unique body features such as voice, retina, fingerprint, hand geometry or signature, activate these locks. This system is used in instances when extremely sensitive facilities must be protected such as in the military.

Electronic door lock This system uses a magnetic or embedded chip based plastic card key or token entered into a sensor reader to gain access. A special code internally stored in the card or token is read by sensor device that then activates the door locking mechanism.

The Combination door lock or cipher lock uses a numeric key pad or dial to gain entry, and is often seen at airport gate entry doors and smaller server rooms. The combination should be changed at regular interval or

whenever an employee with access is transferred, fired or subject to disciplinary action. This reduces risk of the combination being known by unauthorized people.

The following were incorrect answers:

Bolting door lock These locks required the traditional metal key to gain entry. The key should be stamped "do not duplicate" and should be stored and issued under strict management control.

Biometric door lock An individual's unique body features such as voice, retina, fingerprint, hand geometry or signature, activate these locks. This system is used in instances when extremely sensitive facilities must be protected such as in the military.

The Combination door lock or cipher lock uses a numeric key pad or dial to gain entry, and is often seen at airport gate entry doors and smaller server rooms. The combination should be changed at regular interval or whenever an employee with access is transferred, fired or subject to disciplinary action. This reduces risk of the combination being known by unauthorized people.

CISA review manual 2014 Page number 376

QUESTION 468

COBIT 5 separates information goals into three sub-dimensions of quality. Which of the following sub- dimension of COBIT 5 describes the extent to which data values are in conformance with the actual true value?

- A. Intrinsic quality
- B. Contextual and representational quality
- C. Security quality
- D. Accessibility quality

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Three sub-dimensions of quality in COBIT 5 are as follows:

1. Intrinsic quality The extent to which data values are in conformance with the actual or true values. It includes

Accuracy The extent to which information is correct or accurate and reliable **Objectivity** The extent to which information is unbiased, unprejudiced and impartial. **Believability** The extent to which information is regarded as true and credible. **Reputation** The extent to which information is highly regarded in terms of its source or content.

2. Contextual and Representational Quality The extent to which information is applicable to the task of the information user and is presented in an intelligible and clear manner, reorganizing that information quality depends on the context of use. It includes

Relevancy The extent to which information is applicable and helpful for the task at hand. **Completeness** The extent to which information is not missing and is of sufficient depth and breadth for the task at hand

Currency The extent to which information is sufficiently up to date for task at hand. **Appropriate amount of information** The extent to which the volume of information is appropriate for the task at hand

Consistent Representation The extent to which information is presented in the same format. **Interpretability** The extent to which information is in appropriate languages, symbols and units, with clear

definitions.

Understandability - The extent to which information is easily comprehended. **Ease of manipulation** The extent to which information is easy to manipulate and apply to different tasks.

3. Security/accessibility quality The extent to which information is available or obtainable. It includes:

Availability/timeliness The extent to which information is available when required, or easily available when required, or easily and quickly retrievable.

Restricted Access The extent to which access to information is restricted appropriately to authorize parties.

The following were incorrect answers:

Contextual and representational quality - The extent to which information is applicable to the task of the information user and is presented in an intelligible and clear manner, reorganizing that information quality depends on the context of use.

Security Quality or Accessibility quality -The extent to which information is available or obtainable.
CISA review manual 2014 Page number 310

QUESTION 469

Which of the following attack redirects outgoing message from the client back onto the client, preventing outside access as well as flooding the client with the sent packets?

- A. Banana attack
- B. Brute force attack
- C. Buffer overflow
- D. Pulsing Zombie

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A "banana attack" is another particular type of DoS. It involves redirecting outgoing messages from the client back onto the client, preventing outside access, as well as flooding the client with the sent packets.

The Banana attack uses a router to change the destination address of a frame. In the Banana attack:

A compromised router copies the source address on an inbound frame into the destination address.

The outbound frame bounces back to the sender.

This sender is flooded with frames and consumes so many resources that valid service requests can no longer be processed.

The following answers are incorrect:

Brute force attack - Brute force (also known as brute force cracking) is a trial and error method used by application programs to decode encrypted data such as passwords or Data Encryption Standard (DES) keys, through exhaustive effort (using brute force) rather than employing intellectual strategies. Just as a criminal might break into, or "crack" a safe by trying many possible combinations, a brute force cracking application proceeds through all possible combinations of legal characters in sequence. Brute force is considered to be an infallible, although time-consuming, approach.

Buffer overflow - A buffer overflow occurs when a program or process tries to store more data in a buffer (temporary data storage area) than it was intended to hold. Since buffers are created to contain a finite amount

of data, the extra information - which has to go somewhere - can overflow into adjacent buffers, corrupting or overwriting the valid data held in them. Although it may occur accidentally through programming error, buffer overflow is an increasingly common type of security attack on data integrity.

Pulsing Zombie - A Dos attack in which a network is subjected to hostile pinging by different attacker computer over an extended time period.
CISA review manual 2014 Page number 321

QUESTION 470

Which of the following attack is against computer network and involves fragmented or invalid ICMP packets sent to the target?

- A. Nuke attack
- B. Brute force attack
- C. Buffer overflow
- D. Pulsing Zombie

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A Nuke attack is an old denial-of-service attack against computer networks consisting of fragmented or otherwise invalid ICMP packets sent to the target, achieved by using a modified ping utility to repeatedly send this corrupt data, thus slowing down the affected computer until it comes to a complete stop.

A specific example of a nuke attack that gained some prominence is the Win Nuke, which exploited the vulnerability in the NetBIOS handler in Windows 95. A string of out-of-band data was sent to TCP port 139 of the victim's machine, causing it to lock up and display a Blue Screen of Death (BSOD).

The following answers are incorrect:

Brute force attack - Brute force (also known as brute force cracking) is a trial and error method used by application programs to decode encrypted data such as passwords or Data Encryption Standard (DES) keys, through exhaustive effort (using brute force) rather than employing intellectual strategies. Just as a criminal might break into, or "crack" a safe by trying many possible combinations, a brute force cracking application proceeds through all possible combinations of legal characters in sequence. Brute force is considered to be an infallible, although time-consuming, approach.

Buffer overflow - A buffer overflow occurs when a program or process tries to store more data in a buffer (temporary data storage area) than it was intended to hold. Since buffers are created to contain a finite amount of data, the extra information - which has to go somewhere - can overflow into adjacent buffers, corrupting or overwriting the valid data held in them. Although it may occur accidentally through programming error, buffer overflow is an increasingly common type of security attack on data integrity.

Pulsing Zombie - A Dos attack in which a network is subjected to hostile pinging by different attacker computer over an extended time period.
CISA review manual 2014 Page number 322

QUESTION 471

Which of the following attack involves sending forged ICMP Echo Request packets to the broadcast address on multiple gateways in order to illicit responses from the computers behind the gateway where they all respond back with ICMP Echo Reply packets to the source IP address of the ICMP Echo Request packets?

- A. Reflected attack

- B. Brute force attack
- C. Buffer overflow
- D. Pulsing Zombie

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

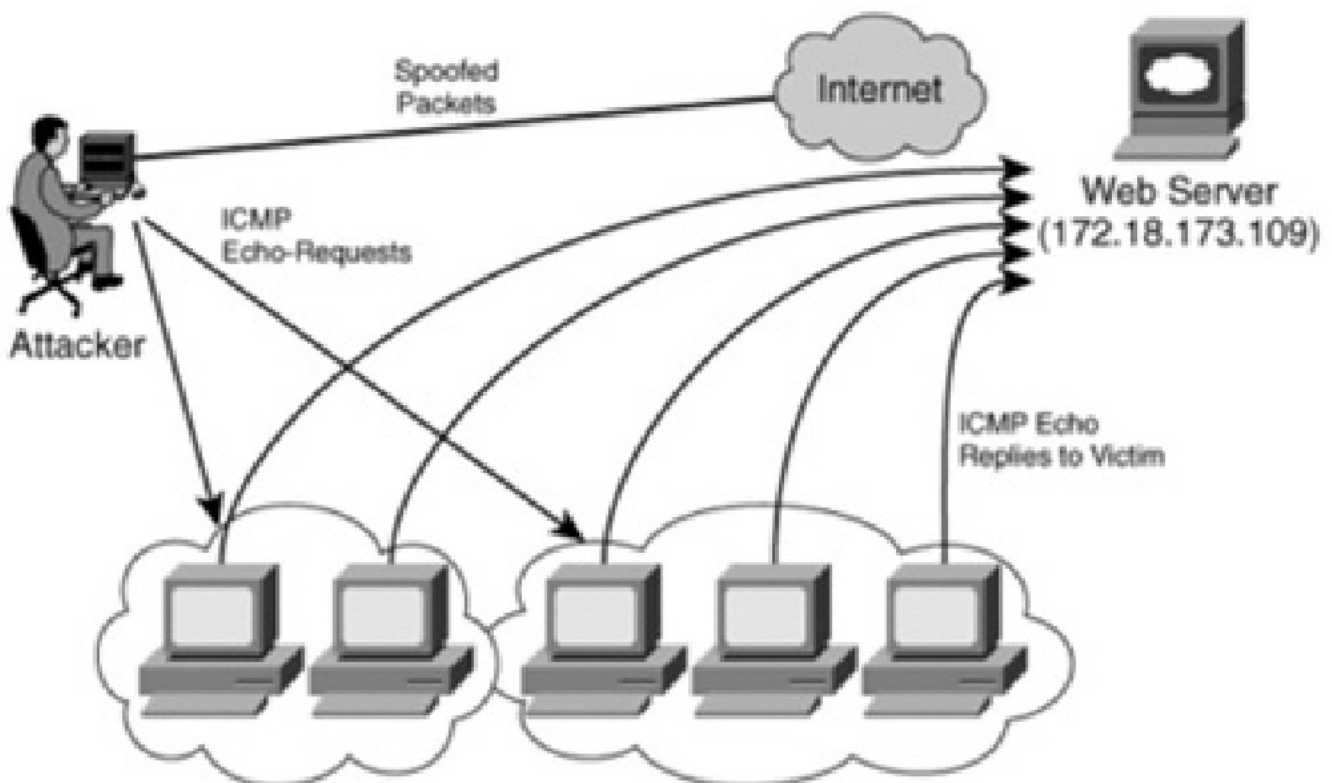
Reflected attack involves sending forged requests to a large number of computers that will reply to the requests. The source IP address is spoofed to that of the targeted victim, causing replies to flood.

A distributed denial of service attack may involve sending forged requests of some type to a very large number of computers that will reply to the requests. Using Internet Protocol address spoofing, the source address is set to that of the targeted victim, which means all the replies will go to (and flood) the target. (This reflected attack form is sometimes called a "DRDOS".

ICMP Echo Request attacks (Smurf Attack) can be considered one form of reflected attack, as the flooding host(s) send Echo Requests to the broadcast addresses of mix-configured networks, thereby enticing hosts to send Echo Reply packets to the victim. Some early DDoS programs implemented a distributed form of this attack.

In the surf attack, the attacker sends an ICMP ECHO REQUEST packet with a spoofed source address to a victim's network broadcast address. This means that each system on the victim's subnet receives an ICMP ECHO REQUEST packet. Each system then replies to that request with an ICMP ECHO REPLY packet to the spoof address provided in the packets--which is the victim's address. All of these response packets go to the victim system and overwhelm it because it is being bombarded with packets it does not necessarily know how to process. The victim system may freeze, crash, or reboot. The Smurf attack is illustrated in Figure below:

surf-attack



The following answers are incorrect:

Brute force attack - Brute force (also known as brute force cracking) is a trial and error method used by application programs to decode encrypted data such as passwords or Data Encryption Standard (DES) keys, through exhaustive effort (using brute force) rather than employing intellectual strategies. Just as a criminal

might break into, or "crack" a safe by trying many possible combinations, a brute force cracking application proceeds through all possible combinations of legal characters in sequence. Brute force is considered to be an infallible, although time-consuming, approach.

Buffer overflow - A buffer overflow occurs when a program or process tries to store more data in a buffer (temporary data storage area) than it was intended to hold. Since buffers are created to contain a finite amount of data, the extra information - which has to go somewhere - can overflow into adjacent buffers, corrupting or overwriting the valid data held in them. Although it may occur accidentally through programming error, buffer overflow is an increasingly common type of security attack on data integrity.

Pulsing Zombie - A Dos attack in which a network is subjected to hostile pinging by different attacker computer over an extended time period.
 CISA review manual 2014 Page number 322

QUESTION 472

During an IS audit, auditor has observed that authentication and authorization steps are split into two functions and there is a possibility to force the authorization step to be completed before the authentication step. Which of the following technique an attacker could user to force authorization step before authentication?

- A. Eavesdropping
- B. Traffic analysis
- C. Masquerading
- D. Race Condition

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A race condition is when processes carry out their tasks on a shared resource in an incorrect order. A race condition is possible when two or more processes use a shared resource, as in data within a variable. It is important that the processes carry out their functionality in the correct sequence. If process 2 carried out its task on the data before process 1, the result will be much different than if process1 carried out its tasks on the data before process 2.

In software, when the authentication and authorization steps are split into two functions, there is a possibility an attacker could use a race condition to force the authorization step to be completed before the authentication step. This would be a flaw in the software that the attacker has figured out how to exploit. A race condition occurs when two or more processes use the same resource and the sequences of steps within the software can be carried out in an improper order, something that can drastically affect the output. So, an attacker can force the authorization step to take place before the authentication step and gain unauthorized access to a resource.

The following answers are incorrect:

Eavesdropping - is the act of secretly listening to the private conversation of others without their consent, as defined by Black's Law Dictionary. This is commonly thought to be unethical and there is an old adage that "eavesdroppers seldom hear anything good of themselves...eavesdroppers always try to listen to matters that concern them."

Traffic analysis - is the process of intercepting and examining messages in order to deduce information from patterns in communication. It can be performed even when the messages are encrypted and cannot be decrypted. In general, the greater the number of messages observed, or even intercepted and stored, the more can be inferred from the traffic. Traffic analysis can be performed in the context of military intelligence, counter-intelligence, or pattern-of-life analysis, and is a concern in computer security.

Masquerading - A masquerade attack is an attack that uses a fake identity, such as a network identity, to gain unauthorized access to personal computer information through legitimate access identification. If an authorization process is not fully protected, it can become extremely vulnerable to a masquerade attack. Masquerade attacks can be perpetrated using stolen passwords and logons, by locating gaps in programs, or by finding a way around the authentication process. The attack can be triggered either by someone within the organization or by an outsider if the organization is connected to a public network. The amount of access masquerade attackers get depends on the level of authorization they've managed to attain. As such, masquerade attackers can have a full smorgasbord of cyber crime opportunities if they've gained the highest access authority to a business organization. Personal attacks, although less common, can also be harmful.

CISA review manual 2014 Page number 324

Official ISC2 guide to CISSP CBK 3rd Edition Page number 66

CISSP All-In-One Exam guide 6th Edition Page Number 161

QUESTION 473

Which of the following attack is also known as Time of Check(TOC)/Time of Use(TOU)?

- A. Eavesdropping
- B. Traffic analysis
- C. Masquerading
- D. Race Condition

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A Race Condition attack is also known as Time of Check(TOC)/Time of Use(TOU).

A race condition is when processes carry out their tasks on a shared resource in an incorrect order. A race condition is possible when two or more processes use a shared resource, as in data within a variable. It is important that the processes carry out their functionality in the correct sequence. If process 2 carried out its task on the data before process 1, the result will be much different than if process1 carried out its tasks on the data before process 2.

In software, when the authentication and authorization steps are split into two functions, there is a possibility an attacker could use a race condition to force the authorization step to be completed before the authentication step. This would be a flaw in the software that the attacker has figured out how to exploit. A race condition occurs when two or more processes use the same resource and the sequences of steps within the software can be carried out in an improper order, something that can drastically affect the output. So, an attacker can force the authorization step to take place before the authentication step and gain unauthorized access to a resource.

The following answers are incorrect:

Eavesdropping - is the act of secretly listening to the private conversation of others without their consent, as defined by Black's Law Dictionary. This is commonly thought to be unethical and there is an old adage that "eavesdroppers seldom hear anything good of themselves...eavesdroppers always try to listen to matters that concern them."

Traffic analysis - is the process of intercepting and examining messages in order to deduce information from patterns in communication. It can be performed even when the messages are encrypted and cannot be decrypted. In general, the greater the number of messages observed, or even intercepted and stored, the more can be inferred from the traffic. Traffic analysis can be performed in the context of military intelligence, counter-intelligence, or pattern-of-life analysis, and is a concern in computer security.

Masquerading - A masquerade attack is an attack that uses a fake identity, such as a network identity, to gain unauthorized access to personal computer information through legitimate access identification. If an authorization process is not fully protected, it can become extremely vulnerable to a masquerade attack. Masquerade attacks can be perpetrated using stolen passwords and logons, by locating gaps in programs, or by finding a way around the authentication process. The attack can be triggered either by someone within the organization or by an outsider if the organization is connected to a public network. The amount of access masquerade attackers get depends on the level of authorization they've managed to attain. As such, masquerade attackers can have a full smorgasbord of cyber crime opportunities if they've gained the highest access authority to a business organization. Personal attacks, although less common, can also be harmful.

CISA review manual 2014 Page number 324

Official ISC2 guide to CISSP CBK 3rd Edition Page number 66

CISSP All-In-One Exam guide 6th Edition Page Number 161

QUESTION 474

Which of the following attack occurs when a malicious action is performed by invoking the operating system to execute a particular system call?

- A. Eavesdropping
- B. Traffic analysis
- C. Masquerading
- D. Interrupt attack

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An Interrupt attack occurs when a malicious action is performed by invoking the operating system to execute a particular system call.

Example: A boot sector virus typically issues an interrupt to execute a write to the boot sector.

The following answers are incorrect:

Eavesdropping - is the act of secretly listening to the private conversation of others without their consent, as defined by Black's Law Dictionary. This is commonly thought to be unethical and there is an old adage that "eavesdroppers seldom hear anything good of themselves...eavesdroppers always try to listen to matters that concern them."

Traffic analysis - is the process of intercepting and examining messages in order to deduce information from patterns in communication. It can be performed even when the messages are encrypted and cannot be decrypted. In general, the greater the number of messages observed, or even intercepted and stored, the more can be inferred from the traffic. Traffic analysis can be performed in the context of military intelligence, counter-intelligence, or pattern-of-life analysis, and is a concern in computer security.

Masquerading - A masquerade attack is an attack that uses a fake identity, such as a network identity, to gain unauthorized access to personal computer information through legitimate access identification. If an authorization process is not fully protected, it can become extremely vulnerable to a masquerade attack. Masquerade attacks can be perpetrated using stolen passwords and logons, by locating gaps in programs, or by finding a way around the authentication process. The attack can be triggered either by someone within the organization or by an outsider if the organization is connected to a public network. The amount of access masquerade attackers get depends on the level of authorization they've managed to attain. As such, masquerade attackers can have a full smorgasbord of cyber crime opportunities if they've gained the highest

access authority to a business organization. Personal attacks, although less common, can also be harmful.
CISA review manual 2014 Page number 322

QUESTION 475

Which of the following attack includes social engineering, link manipulation or web site forgery techniques?

- A. surf attack
- B. Traffic analysis
- C. Phishing
- D. Interrupt attack

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Phishing technique include social engineering, link manipulation or web site forgery techniques.

For your exam you should know the information below:

Phishing is the attempt to acquire sensitive information such as usernames, passwords, and credit card details (and sometimes, indirectly, money) by masquerading as a trustworthy entity in an electronic communication. Communications purporting to be from popular social web sites, auction sites, banks, online payment processors or IT administrators are commonly used to lure unsuspecting public. Phishing emails may contain links to websites that are infected with malware. Phishing is typically carried out by email spoofing or instant messaging, and it often directs users to enter details at a fake website whose look and feel are almost identical to the legitimate one. Phishing is an example of social engineering techniques used to deceive users, and exploits the poor usability of current web security technologies. Attempts to deal with the growing number of reported phishing incidents include legislation, user training, public awareness, and technical security measures.

Spear phishing - Phishing attempts directed at specific individuals or companies have been termed spear phishing. Attackers may gather personal information about their target to increase their probability of success.

Link manipulation

Most methods of phishing use some form of technical deception designed to make a link in an email (and the spoofed website it leads to) appear to belong to the spoofed organization. Misspelled URLs or the use of sub domains are common tricks used by phishes. In the following example URL, <http://www.yourbank.example.com/>, it appears as though the URL will take you to the example section of the your bank website; actually this URL points to the "your bank" (i.e. phishing) section of the example website. Another common trick is to make the displayed text for a link (the text between the tags) suggest a reliable destination, when the link actually goes to the phishes' site. The following example link, [//en.wikipedia.org/wiki/ Genuine](http://en.wikipedia.org/wiki/Genuine), appears to direct the user to an article entitled "Genuine"; clicking on it will in fact take the user to the article entitled "Deception". In the lower left hand corner of most browsers users can preview and verify where the link is going to take them. Hovering your cursor over the link for a couple of seconds may do a similar thing, but this can still be set by the phishes through the HTML tooltip tag.

Website forgery

Once a victim visits the phishing website, the deception is not over. Some phishing scams use JavaScript commands in order to alter the address bar. This is done either by placing a picture of a legitimate URL over the address bar, or by closing the original bar and opening up a new one with the legitimate URL.

An attacker can even use flaws in a trusted website's own scripts against the victim. These types of attacks (known as cross-site scripting) are particularly problematic, because they direct the user to sign in at their bank or service's own web page, where everything from the web address to the security certificates appears correct.

In reality, the link to the website is crafted to carry out the attack, making it very difficult to spot without specialist knowledge.

The following answers are incorrect:

Smurf Attack Occurs when mis-configured network device allow packet to be sent to all hosts on a particular network via the broadcast address of the network

Traffic analysis - is the process of intercepting and examining messages in order to deduce information from patterns in communication. It can be performed even when the messages are encrypted and cannot be decrypted. In general, the greater the number of messages observed, or even intercepted and stored, the more can be inferred from the traffic. Traffic analysis can be performed in the context of military intelligence, counter-intelligence, or pattern-of-life analysis, and is a concern in computer security.

Interrupt attack- Interrupt attack occurs when a malicious action is performed by invoking the operating system to execute a particular system call.

CISA review manual 2014 Page number 323

Official ISC2 guide to CISSP CBK 3rd Edition Page number 493

<http://en.wikipedia.org/wiki/Phishing>

QUESTION 476

Which of the following attack is MOSTLY performed by an attacker to steal the identity information of a user such as credit card number, passwords, etc?

- A. Smurf attack
- B. Traffic analysis
- C. Harming
- D. Interrupt attack

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Harming is a cyber attack intended to redirect a website's traffic to another, bogus site. Harming can be conducted either by changing the hosts file on a victim's computer or by exploitation of a vulnerability in DNS server software. DNS servers are computers responsible for resolving Internet names into their real IP addresses. Compromised DNS servers are sometimes referred to as "poisoned". Harming requires unprotected access to target a computer, such as altering a customer's home computer, rather than a corporate business server.

The term "phrasing" is a neologism based on the words "farming" and "phishing". Phishing is a type of social-engineering attack to obtain access credentials, such as user names and passwords. In recent years, both phrasing and phishing have been used to gain information for online identity theft. Phrasing has become of major concern to businesses hosting ecommerce and online banking websites. Sophisticated measures known as anti-harming are required to protect against this serious threat. Antivirus software and spyware removal software cannot protect against harming.

For your exam you should know the information below:

Phishing is the attempt to acquire sensitive information such as usernames, passwords, and credit card details (and sometimes, indirectly, money) by masquerading as a trustworthy entity in an electronic communication. Communications purporting to be from popular social web sites, auction sites, banks, online payment processors or IT administrators are commonly used to lure unsuspecting public. Phishing emails may contain

links to websites that are infected with malware. Phishing is typically carried out by email spoofing or instant messaging, and it often directs users to enter details at a fake website whose look and feel are almost identical to the legitimate one. Phishing is an example of social engineering techniques used to deceive users, and exploits the poor usability of current web security technologies. Attempts to deal with the growing number of reported phishing incidents include legislation, user training, public awareness, and technical security measures.

Spear phishing - Phishing attempts directed at specific individuals or companies have been termed spear phishing. Attackers may gather personal information about their target to increase their probability of success.

Link manipulation

Most methods of phishing use some form of technical deception designed to make a link in an email (and the spoofed website it leads to) appear to belong to the spoofed organization. Misspelled URLs or the use of sub domains are common tricks used by phishes. In the following example URL, <http://www.yourbank.example.com/>, it appears as though the URL will take you to the example section of your bank website; actually this URL points to the "your bank" (i.e. phishing) section of the example website. Another common trick is to make the displayed text for a link (the text between the `<a>` tags) suggest a reliable destination, when the link actually goes to the phishes' site. The following example link, [//en.wikipedia.org/wiki/ Genuine](http://en.wikipedia.org/wiki/Genuine), appears to direct the user to an article entitled "Genuine"; clicking on it will in fact take the user to the article entitled "Deception". In the lower left hand corner of most browsers users can preview and verify where the link is going to take them. Hovering your cursor over the link for a couple of seconds may do a similar thing, but this can still be set by the phishes through the HTML tooltip tag.

Website forgery

Once a victim visits the phishing website, the deception is not over. Some phishing scams use JavaScript commands in order to alter the address bar. This is done either by placing a picture of a legitimate URL over the address bar, or by closing the original bar and opening up a new one with the legitimate URL.

An attacker can even use flaws in a trusted website's own scripts against the victim. These types of attacks (known as cross-site scripting) are particularly problematic, because they direct the user to sign in at their bank or service's own web page, where everything from the web address to the security certificates appears correct. In reality, the link to the website is crafted to carry out the attack, making it very difficult to spot without specialist knowledge.

The following answers are incorrect:

Smurf Attack Occurs when mis-configured network device allow packet to be sent to all hosts on a particular network via the broadcast address of the network

Traffic analysis - is the process of intercepting and examining messages in order to deduce information from patterns in communication. It can be performed even when the messages are encrypted and cannot be decrypted. In general, the greater the number of messages observed, or even intercepted and stored, the more can be inferred from the traffic. Traffic analysis can be performed in the context of military intelligence, counter-intelligence, or pattern-of-life analysis, and is a concern in computer security.

Interrupt attack- Interrupt attack occurs when a malicious action is performed by invoking the operating system to execute a particular system call.

CISA review manual 2014 Page number 323

Official ISC2 guide to CISSP CBK 3rd Edition Page number 326

<http://en.wikipedia.org/wiki/Phishing>

<http://en.wikipedia.org/wiki/Pharming>

QUESTION 477

Which of the following biometrics methods provides the HIGHEST accuracy and is LEAST accepted by users?

- A. Palm Scan
- B. Hand Geometry
- C. Fingerprint
- D. Retina scan

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Retina based biometric involves analyzing the layer of blood vessels situated at the back of the eye. An established technology, this technique involves using a low-intensity light source through an optical coupler to scan the unique patterns of the retina. Retinal scanning can be quite accurate but does require the user to look into a receptacle and focus on a given point. This is not particularly convenient if you wear glasses or are concerned about having close contact with the reading device. For these reasons, retinal scanning is not warmly accepted by all users, even though the technology itself can work well.

For your exam you should know the information below:

Biometrics

Biometrics verifies an individual's identity by analyzing a unique personal attribute or behavior, which is one of the most effective and accurate methods of verifying identification and not well received by society. Biometrics is a very sophisticated technology; thus, it is much more expensive and complex than the other types of identity verification processes. A biometric system can make authentication decisions based on an individual's behavior, as in signature dynamics, but these can change over time and possibly be forged. Biometric systems that base authentication decisions on physical attributes (such as iris, retina, or fingerprint) provide more accuracy because physical attributes typically don't change, absent some disfiguring injury, and are harder to impersonate

Biometrics is typically broken up into two different categories. The first is the physiological. These are traits that are physical attributes unique to a specific individual. Fingerprints are a common example of a physiological trait used in biometric systems. The second category of biometrics is known as behavioral. The behavioral authentication is also known as continuous authentication. The behavioral/continuous authentication prevents session hijacking attack. This is based on a characteristic of an individual to confirm his identity. An example is signature Dynamics. Physiological is "what you are" and behavioral is "what you do."

When a biometric system rejects an authorized individual, it is called a Type I error (false rejection rate). When the system accepts impostors who should be rejected, it is called a Type II error (false acceptance rate). The goal is to obtain low numbers for each type of error, but Type II errors are the most dangerous and thus the most important to avoid.

When comparing different biometric systems, many different variables are used, but one of the most important metrics is the crossover error rate (CER). This rating is stated as a percentage and represents the point at which the false rejection rate equals the false acceptance rate. This rating is the most important measurement when determining the system's accuracy. A biometric system that delivers a CER of 3 will be more accurate than a system that delivers a CER of 4. Crossover error rate (CER) is also called equal error rate (EER).

Throughput describes the process of authenticating to a biometric system. This is also referred to as the biometric system response time. The primary consideration that should be put into the purchasing and implementation of biometric access control are user acceptance, accuracy and processing speed.

Biometric Considerations

In addition to the access control elements of a biometric system, there are several other considerations that are important to the integrity of the control environment. These are:

- Resistance to counterfeiting
- Data storage requirements
- User acceptance
- Reliability and
- Target User and approach

Fingerprint

Fingerprints are made up of ridge endings and bifurcations exhibited by friction ridges and other detailed characteristics called minutiae. It is the distinctiveness of these minutiae that gives each individual a unique fingerprint. An individual places his finger on a device that reads the details of the fingerprint and compares this to a reference file. If the two match, the individual's identity has been verified.

Palm Scan

The palm holds a wealth of information and has many aspects that are used to identify an individual. The palm has creases, ridges, and grooves throughout that are unique to a specific person. The palm scan also includes the fingerprints of each finger. An individual places his hand on the biometric device, which scans and captures this information. This information is compared to a reference file, and the identity is either verified or rejected.

Hand Geometry

The shape of a person's hand (the shape, length, and width of the hand and fingers) defines hand geometry. This trait differs significantly between people and is used in some biometric systems to verify identity. A person places her hand on a device that has grooves for each finger. The system compares the geometry of each finger, and the hand as a whole, to the information in a reference file to verify that person's identity.

Retina Scan

A system that reads a person's retina scans the blood-vessel pattern of the retina on the backside of the eyeball. This pattern has shown to be extremely unique between different people. A camera is used to project a beam inside the eye and capture the pattern and compare it to a reference file recorded previously.

Iris Scan

An iris scan is a passive biometric control

The iris is the colored portion of the eye that surrounds the pupil. The iris has unique patterns, rifts, colors, rings, coronas, and furrows. The uniqueness of each of these characteristics within the iris is captured by a camera and compared with the information gathered during the enrollment phase. When using an iris pattern biometric system, the optical unit must be positioned so the sun does not shine into the aperture; thus, when implemented, it must have proper placement within the facility.

Signature Dynamics

When a person signs a signature, usually they do so in the same manner and speed each time. Signing a signature produces electrical signals that can be captured by a biometric system. The physical motions performed when someone is signing a document create these electrical signals. The signals provide unique characteristics that can be used to distinguish one individual from another. Signature dynamics provides more information than a static signature, so there are more variables to verify when confirming an individual's identity and more assurance that this person is who he claims to be.

Keystroke Dynamics

Whereas signature dynamics is a method that captures the electrical signals when a person signs a name, keystroke dynamics captures electrical signals when a person types a certain phrase. As a person types a specified phrase, the biometric system captures the speed and motions of this action. Each individual has a certain style and speed, which translate into unique signals. This type of authentication is more effective than typing in a password, because a password is easily obtainable. It is much harder to repeat a person's typing style than it is to acquire a password.

Voice Print

People's speech sounds and patterns have many subtle distinguishing differences. A biometric system that is programmed to capture a voice print and compare it to the information held in a reference file can differentiate one individual from another. During the enrollment process, an individual is asked to say several different words.

Facial Scan

A system that scans a person's face takes many attributes and characteristics into account. People have different bone structures, nose ridges, eye widths, forehead sizes, and chin shapes. These are all captured during a facial scan and compared to an earlier captured scan held within a reference record. If the information is a match, the person is positively identified.

Hand Topography

Whereas hand geometry looks at the size and width of an individual's hand and fingers, hand topology looks at the different peaks and valleys of the hand, along with its overall shape and curvature. When an individual wants to be authenticated, she places her hand on the system. Off to one side of the system, a camera snaps a side-view picture of the hand from a different view and angle than that of systems that target hand geometry, and thus captures different data. This attribute is not unique enough to authenticate individuals by itself and is commonly used in conjunction with hand geometry.

Vascular Scan

Vascular Scan uses the blood vessel under the first layer of skin.

The following answers are incorrect:

Fingerprint - Fingerprints are made up of ridge endings and bifurcations exhibited by friction ridges and other detailed characteristics called minutiae. It is the distinctiveness of these minutiae that gives each individual a unique fingerprint. An individual places his finger on a device that reads the details of the fingerprint and compares this to a reference file. If the two match, the individual's identity has been verified.

Hand Geometry - The shape of a person's hand (the shape, length, and width of the hand and fingers) defines hand geometry. This trait differs significantly between people and is used in some biometric systems to verify identity. A person places her hand on a device that has grooves for each finger. The system compares the geometry of each finger, and the hand as a whole, to the information in a reference file to verify that person's identity.

Palm Scan - The palm holds a wealth of information and has many aspects that are used to identify an individual. The palm has creases, ridges, and grooves throughout that are unique to a specific person. The palm scan also includes the fingerprints of each finger. An individual places his hand on the biometric device, which scans and captures this information. This information is compared to a reference file, and the identity is either verified or rejected.

QUESTION 478

Which of the following attack could be avoided by creating more security awareness in the organization and provide adequate security knowledge to all employees?

- A. surf attack
- B. Traffic analysis
- C. Phishing
- D. Interrupt attack

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Phishing techniques include social engineering, link manipulation, spear phishing, whaling, dishing, or web site forgery techniques.

For your exam you should know the information below:

Phishing is the attempt to acquire sensitive information such as usernames, passwords, and credit card details (and sometimes, indirectly, money) by masquerading as a trustworthy entity in an electronic communication. Communications purporting to be from popular social web sites, auction sites, banks, online payment

processors or IT administrators are commonly used to lure unsuspecting public. Phishing emails may contain links to websites that are infected with malware. Phishing is typically carried out by email spoofing or instant messaging, and it often directs users to enter details at a fake website whose look and feel are almost identical to the legitimate one. Phishing is an example of social engineering techniques used to deceive users, and exploits the poor usability of current web security technologies. Attempts to deal with the growing number of reported phishing incidents include legislation, user training, public awareness, and technical security measures.

Spear phishing

Phishing attempts directed at specific individuals or companies have been termed spear phishing. Attackers may gather personal information about their target to increase their probability of success.

Link manipulation

Most methods of phishing use some form of technical deception designed to make a link in an email (and the spoofed website it leads to) appear to belong to the spoofed organization. Misspelled URLs or the use of sub domains are common tricks used by phishes. In the following example URL, <http://www.yourbank.example.com/>, it appears as though the URL will take you to the example section of your bank website; actually this URL points to the "your bank" (i.e. phishing) section of the example website. Another common trick is to make the displayed text for a link (the text between the tags) suggest a reliable destination, when the link actually goes to the phishes' site. The following example link, [//en.wikipedia.org/wiki/Genuine](http://en.wikipedia.org/wiki/Genuine), appears to direct the user to an article entitled "Genuine"; clicking on it will in fact take the user to the article entitled "Deception". In the lower left hand corner of most browsers users can preview and verify where the link is going to take them. Hovering your cursor over the link for a couple of seconds may do a similar thing, but this can still be set by the phishes through the HTML tooltip tag.

Website forgery

Once a victim visits the phishing website, the deception is not over. Some phishing scams use JavaScript commands in order to alter the address bar. This is done either by placing a picture of a legitimate URL over the address bar, or by closing the original bar and opening up a new one with the legitimate URL.

An attacker can even use flaws in a trusted website's own scripts against the victim. These types of attacks (known as cross-site scripting) are particularly problematic, because they direct the user to sign in at their bank or service's own web page, where everything from the web address to the security certificates appears correct. In reality, the link to the website is crafted to carry out the attack, making it very difficult to spot without specialist knowledge.

The following answers are incorrect:

Smurf Attack - Occurs when mis-configured network device allow packet to be sent to all hosts on a particular network via the broadcast address of the network
Traffic analysis - is the process of intercepting and examining messages in order to deduce information from patterns in communication. It can be performed even when the messages are encrypted and cannot be decrypted. In general, the greater the number of messages observed, or even intercepted and stored, the more can be inferred from the traffic. Traffic analysis can be performed in the context of military intelligence, counter-intelligence, or pattern-of-life analysis, and is a concern in computer security.

Interrupt attack- Interrupt attack occurs when a malicious action is performed by invoking the operating system to execute a particular system call.

CISA review manual 2014 Page number 323

Official ISC2 guide to CISSP CBK 3rd Edition Page number 493

<http://en.wikipedia.org/wiki/Phishing>

QUESTION 479

Which of the following Confidentiality, Integrity, Availability (CIA) attribute supports the principle of least privilege by providing access to information only to authorized and intended users?

- A. Confidentiality
- B. Integrity
- C. Availability
- D. Accuracy

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Confidentiality supports the principle of "least privilege" by providing that only authorized individuals, processes, or systems should have access to information on a need-to-know basis.

The level of access that an authorized individual should have is at the level necessary for them to do their job. In recent years, much press has been dedicated to the privacy of information and the need to protect it from individuals, who may be able to commit crimes by viewing the information.

Identity theft is the act of assuming one's identity through knowledge of confidential information obtained from various sources.

An important measure to ensure confidentiality of information is data classification. This helps to determine who should have access to the information (public, internal use only, or confidential). Identification, authentication, and authorization through access controls are practices that support maintaining the confidentiality of information.

A sample control for protecting confidentiality is to encrypt information. Encryption of information limits the usability of the information in the event it is accessible to

an unauthorized person.

For your exam you should know the information below:

Integrity

Integrity is the principle that information should be protected from intentional, unauthorized, or accidental changes.

Information stored in files, databases, systems, and networks must be relied upon to accurately process transactions and provide accurate information for business decision making. Controls are put in place to ensure that information is modified through accepted practices.

Sample controls include management controls such as segregation of duties, approval checkpoints in the systems development life cycle, and implementation of testing practices that assist in providing information integrity. Well-formed transactions and security of the update programs provide consistent methods of applying changes to systems. Limiting update access to those individuals with a need to access limits the exposure to intentional and unintentional modification.

Availability

Availability is the principle that ensures that information is available and accessible to users when needed.

The two primary areas affecting the availability of systems are:

1. Denial-of-Service attacks and
2. Loss of service due to a disaster, which could be man-made (e.g., poor capacity planning resulting in system crash, outdated hardware, and poor testing resulting in system crash after upgrade) or natural (e.g., earthquake, tornado, blackout, hurricane, fire, and flood).

In either case, the end user does not have access to information needed to conduct business. The criticality of the system to the user and its importance to the survival of the organization will determine how significant the impact of the extended downtime becomes. The lack of appropriate security controls can increase the risk of viruses, destruction of data, external penetrations, or denial-of-service (DOS) attacks. Such events can

prevent the system from being used by normal users.

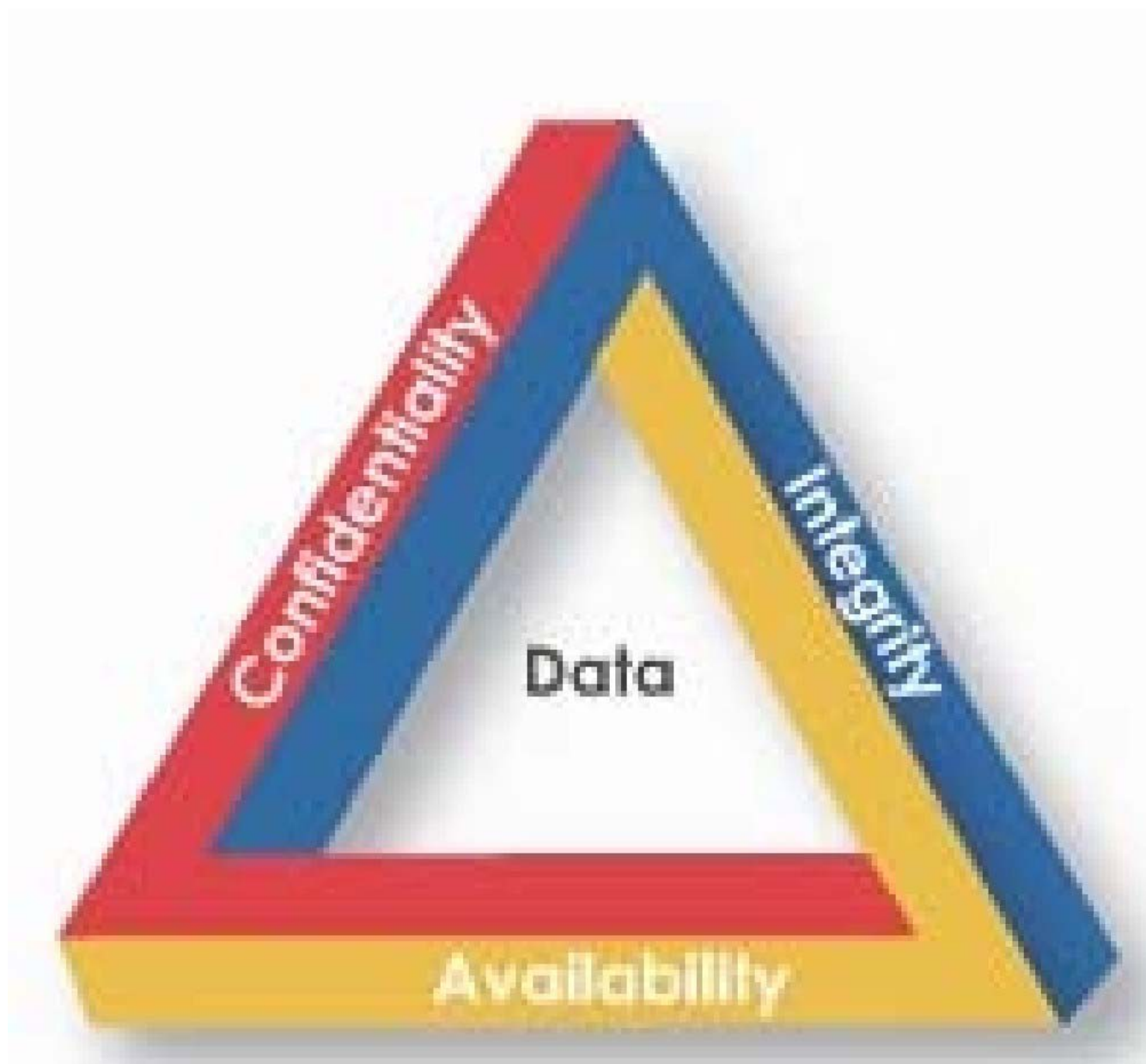
CIA

The following answers are incorrect:

Integrity- Integrity is the principle that information should be protected from intentional, unauthorized, or accidental changes.

Availability - Availability is the principle that ensures that information is available and accessible to users when needed.

Accuracy Accuracy is not a valid CIA attribute.



CISA review manual 2014 Page number 314
Official ISC2 guide to CISSP CBK 3rd Edition Page number 350

QUESTION 480

Which of the following method should be recommended by security professional to erase the data on the magnetic media that would be reused by another employee?

- A. Degaussing
- B. Overwrite every sector of magnetic media with pattern of 1's and 0's
- C. Format magnetic media
- D. Delete File allocation table

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Software tools can provide object reuse assurance. These tools overwrite every sector of magnetic media with a random or predetermined bit pattern. Overwrite methods are effective for all forms of electronic media with the exception of read-only optical media.

For your exam you should know the information below:

When media is to be reassigned (a form of object reuse), it is important that all residual data is carefully removed. Simply deleting files or formatting media does not actually remove the information. File deletion and media formatting often simply remove the pointers to the information. Providing assurance for object reuse requires specialized tools and techniques according to the type of media on which the data resides. Specialized hardware devices known as degaussers can be used to erase data saved to magnetic media. The measure of the amount of energy needed to reduce the magnetic field on the media to zero is known as coercivity. It is important to make sure that the coercivity of the degasser is of sufficient strength to meet object reuse requirements when erasing data. If a degasser is used with insufficient coercivity, then a remanence of the data will exist. Remanence is the measure of the existing magnetic field on the media; it is the residue that remains after an object is degaussed or written over. Data is still recoverable even when the remanence is small. While data remanence exists, there is no assurance of safe object reuse. Some degaussers can destroy drives. The security professional should exercise caution when recommending or using degaussers on media for reuse.

Software tools also exist that can provide object reuse assurance. These tools overwrite every sector of magnetic media with a random or predetermined bit pattern. Overwrite methods are effective for all forms of electronic media with the exception of read-only optical media. There exists a drawback to using overwrite software. During normal write operations with magnetic media, the head of the drive moves back-and-forth across the media as data is written. The track of the head does not usually follow the exact path each time. The result is a miniscule amount of data remanence with each pass. With specialized equipment, it is possible to read data that has been overwritten. To provide higher assurance in this case, it is necessary to overwrite each sector multiple times. Security practitioners should keep in mind that a one-time pass may be acceptable for noncritical information, but sensitive data should be overwritten with multiple passes. Overwrite software can also be used to clear the sectors within solid-state media such as USB thumb drives. It is suggested that physical destruction methods such as incineration or secure recycling should be considered for solid-state media that is no longer used.

The last form of preventing unauthorized access to sensitive data is media destruction. Shredding, burning, grinding, and pulverizing are common methods of physically destroying media. Degaussing can also be a form of media destruction. High-power degausses are so strong in some cases that they can literally bend and warp the platters in a hard drive. Shredding and burning are effective destruction methods for non-rigid magnetic media. Indeed, some shredders are capable of shredding some rigid media such as an optical disk. This may be an effective alternative for any optical media containing nonsensitive information due to the residue size remaining after feeding the disk into the machine. However, the residue size might be too large for media containing sensitive information.

Alternatively, grinding and pulverizing are acceptable choices for rigid and solid-state media. Specialized devices are available for grinding the face of optical media that either sufficiently scratches the surface to render the media unreadable or actually grinds off the data layer of the disk. Several services also exist which will collect drives, destroy them on site if requested and provide certification of completion. It will be the responsibility of the security professional to help, select, and maintain the most appropriate solutions for media cleansing and disposal.

The following answers are incorrect:

Degaussing -Erasing data by applying magnetic field around magnetic media. Degausses device is used to erase the data. Sometime degausses can make magnetic media unusable. So degaussing is not recommended way if magnetic media needs to be reused.

Format magnetic media Formatting magnetic media does not erase all data. Data can be recoverable after formatting using software tools.

Delete File allocation table-It will not erase all data. Data can be recoverable using software tools.

CISA review manual 2014 Page number 338

QUESTION 481

During an IS audit, one of your auditor has observed that some of the critical servers in your organization can be accessed ONLY by using shared/common user name and password. What should be the auditor's PRIMARY concern be with this approach?

- A. Password sharing
- B. Accountability
- C. Shared account management
- D. Difficulty in auditing shared account

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The keyword PRIMARY is used in the question. Accountability should be the primary concern if critical servers can be accessed only by using shared user id and password. It would be very difficult to track the changes done by employee on critical server.

For your exam you should know the information below:

Accountability

Ultimately one of the drivers behind strong identification, authentication, auditing and session management is accountability. Accountability is fundamentally about being able to determine who or what is responsible for an action and can be held responsible. A closely related information assurance topic is non-repudiation.

Repudiation is the ability to deny an action, event, impact or result. Non-repudiation is the process of ensuring a user may not deny an action. Accountability relies heavily on non-repudiation to ensure users, processes and actions may be held responsible for impacts.

The following contribute to ensuring accountability of actions:

Strong identification

Strong authentication

User training and awareness

Comprehensive, timely and thorough monitoring

Accurate and consistent audit logs

Independent audits

Policies enforcing accountability

Organizational behavior supporting accountability

The following answers are incorrect:

The other options are also valid concern. But the primary concern should be accountability.

CISA review manual 2014 Page number 328 and 329

Official ISC2 guide to CISSP CBK 3rd Edition Page number 114

QUESTION 482

Which of the following protocol is PRIMARILY used to provide confidentiality in a web based application thus protecting data sent across a client machine and a server?

- A. SSL
- B. FTP
- C. SSH
- D. S/MIME

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The Secure Socket Layer (SSL) Protocol is primarily used to provide confidentiality to the information sent across clients and servers.

For your exam you should know the information below:

The Secure Sockets Layer (SSL) is a commonly-used protocol for managing the security of a message transmitted over a public network such as the Internet.

SSL has recently been succeeded by Transport Layer Security (TLS), which is based on SSL. SSL uses a program layer located between the Internet's Hypertext Transfer Protocol (HTTP) and Transport Control Protocol (TCP) layers.

SSL is included as part of both the Microsoft and Netscape browsers and most Web server products.

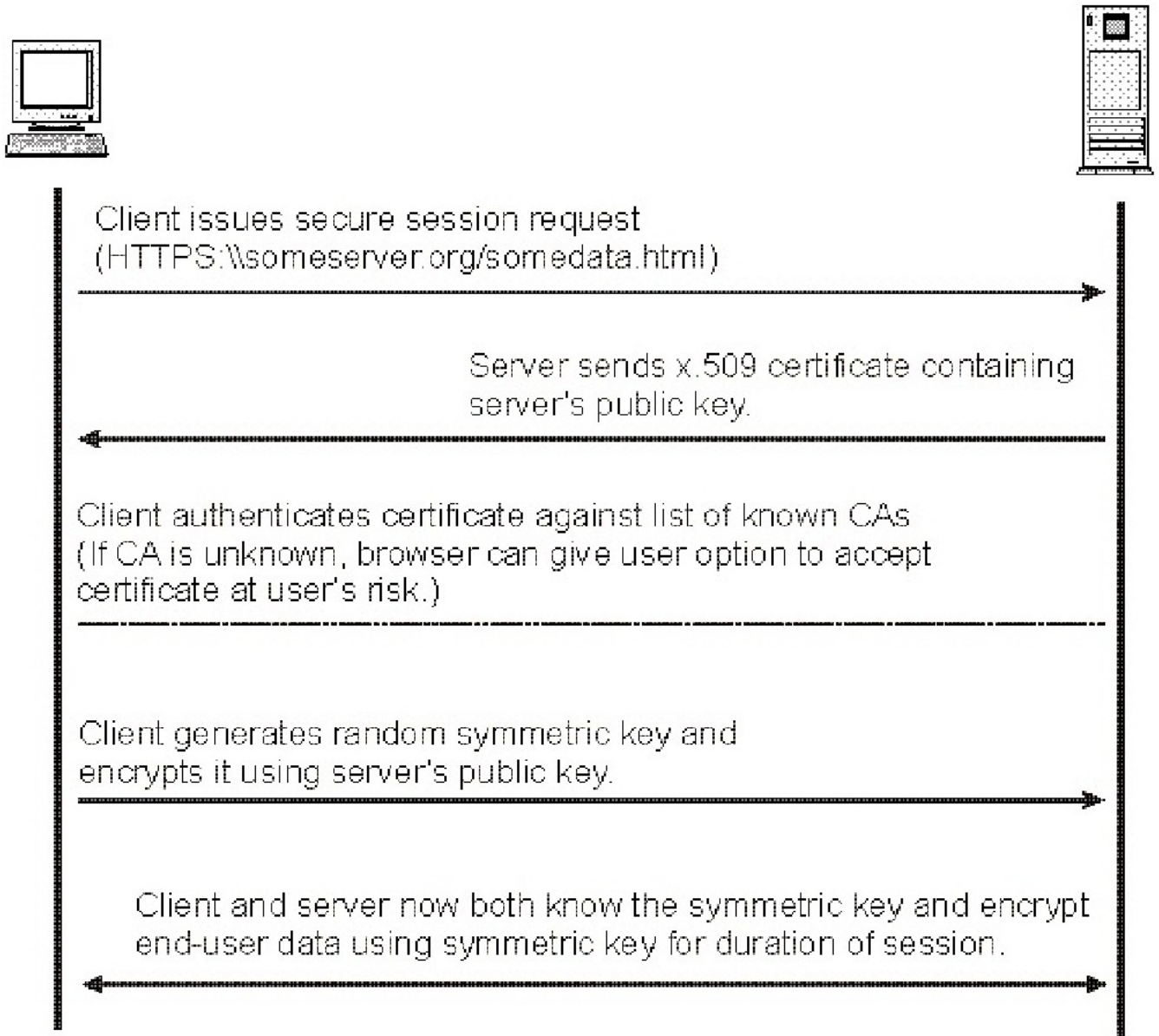
Developed by Netscape, SSL also gained the support of Microsoft and other Internet client/server developers as well and became the de facto standard until evolving into Transport Layer Security. The "sockets" part of the term refers to the sockets method of passing data back and forth between a client and a server program in a network or between program layers in the same computer. SSL uses the public-and-private key encryption system from RSA, which also includes the use of a digital certificate. Later on SSL uses a Session Key along a Symmetric Cipher for the bulk of the data. TLS and SSL are an integral part of most Web browsers (clients) and Web servers. If a Web site is on a server that supports SSL, SSL can be enabled and specific Web pages can be identified as requiring SSL access. Any Web server can be enabled by using Netscape's SSLRef program library which can be downloaded for noncommercial use or licensed for commercial use.

TLS and SSL are not interoperable. However, a message sent with TLS can be handled by a client that handles SSL but not TLS.

The SSL handshake

A HTTP-based SSL connection is always initiated by the client using a URL starting with https:// instead of with http://. At the beginning of an SSL session, an SSL handshake is performed. This handshake produces the cryptographic parameters of the session. A simplified overview of how the SSL handshake is processed is shown in the diagram below.

SSL Handshake



The client sends a client "hello" message that lists the cryptographic capabilities of the client (sorted in client preference order), such as the version of SSL, the cipher suites supported by the client, and the data compression methods supported by the client. The message also contains a 28-byte random number.

The server responds with a server "hello" message that contains the cryptographic method (cipher suite) and the data compression method selected by the server, the session ID, and another random number.

Note:

The client and the server must support at least one common cipher suite, or else the handshake fails. The server generally chooses the strongest common cipher suite.

The server sends its digital certificate. (In this example, the server uses X.509 V3 digital certificates with SSL.)

If the server uses SSL V3, and if the server application (for example, the Web server) requires a digital certificate for client authentication, the server sends a "digital certificate request" message. In the "digital certificate request" message, the server sends a list of the types of digital certificates supported and the distinguished names of acceptable certificate authorities.

The server sends a server "hello done" message and waits for a client response. Upon receipt of the server "hello done" message, the client (the Web browser) verifies the validity of the server's digital certificate and checks that the server's "hello" parameters are acceptable.

If the server requested a client digital certificate, the client sends a digital certificate, or if no suitable digital certificate is available, the client sends a "no digital certificate" alert. This alert is only a warning, but the server application can fail the session if client authentication is mandatory.

The client sends a "client key exchange" message. This message contains the pre-master secret, a 46-byte random number used in the generation of the symmetric encryption keys and the message authentication code (MAC) keys, encrypted with the public key of the server.

If the client sent a digital certificate to the server, the client sends a "digital certificate verify" message signed with the client's private key. By verifying the signature of this message, the server can explicitly verify the ownership of the client digital certificate.

Note:

An additional process to verify the server digital certificate is not necessary. If the server does not have the private key that belongs to the digital certificate, it cannot decrypt the pre-master secret and create the correct keys for the symmetric encryption algorithm, and the handshake fails.

The client uses a series of cryptographic operations to convert the pre-master secret into a master secret, from which all key material required for encryption and message authentication is derived. Then the client sends a "change cipher spec" message to make the server switch to the newly negotiated cipher suite. The next message sent by the client (the "finished" message) is the first message encrypted with this cipher method and keys.

The server responds with a "change cipher spec" and a "finished" message of its own. The SSL handshake ends, and encrypted application data can be sent.

The following answers are incorrect:

FTP - File Transfer Protocol (FTP) is a standard Internet protocol for transmitting files between computers on the Internet. Like the Hypertext Transfer Protocol (HTTP), which transfers displayable Web pages and related files, and the Simple Mail Transfer Protocol (SMTP), which transfers e-mail, FTP is an application protocol that uses the Internet's TCP/IP protocols. FTP is commonly used to transfer Web page files from their creator to the computer that acts as their server for everyone on the Internet. It's also commonly used to download programs and other files to your computer from other servers.

SSH - Secure Shell (SSH) is a cryptographic network protocol for secure data communication, remote command-line login, remote command execution, and other secure network services between two networked computers. It connects, via a secure channel over an insecure network, a server and a client running SSH server and SSH client programs, respectively.

S/MIME - S/MIME (Secure Multi-Purpose Internet Mail Extensions) is a secure method of sending e-mail that uses the Rivest-Shamir-Adelman encryption system. S/MIME is included in the latest versions of the Web browsers from Microsoft and Netscape and has also been endorsed by other vendors that make messaging products. RSA has proposed S/MIME as a standard to the Internet Engineering Task Force (IETF).

CISA review manual 2014 Page number 352

Official ISC2 guide to CISSP CBK 3rd Edition Page number 256

http://publib.boulder.ibm.com/tividd/td/ITAME/SC32-1363-00/en_US/HTML/ss7aumst18.htm

QUESTION 483

Which of the following method is recommended by security professional to PERMANENTLY erase sensitive data on magnetic media?

- A. Degaussing
- B. Overwrite every sector of magnetic media with pattern of 1's and 0's
- C. Format magnetic media
- D. Delete File allocation table

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

PERMANENTLY is the keyword used in the question. You need to find out data removal method which remove data permanently from magnetic media.

Degaussing is the most effective method out of all provided choices to erase sensitive data on magnetic media provided magnetic media is not requiring to be reuse. Some degausses can destroy drives. The security professional should exercise caution when recommending or using degausses on media for reuse.

A device that performs degaussing generates a coercive magnetic force that reduces the magnetic flux density of the storage media to zero. This magnetic force is what properly erases data from media. Data are stored on magnetic media by the representation of the polarization of the atoms. Degaussing changes this polarization (magnetic alignment) by using a type of large magnet to bring it back to its original flux (magnetic alignment).

For your exam you should know the information below:

When media is to be reassigned (a form of object reuse), it is important that all residual data is carefully removed.

Simply deleting files or formatting the media does not actually remove the information. File deletion and media formatting often simply remove the pointers to the information. Providing assurance for object reuse requires specialized tools and techniques according to the type of media on which the data resides.

Specialized hardware devices known as degausses can be used to erase data saved to magnetic media. The measure of the amount of energy needed to reduce the magnetic field on the media to zero is known as coercivity. It is important to make sure that the coercivity of the degasser is of sufficient strength to meet object reuse requirements when erasing data. If a degasser is used with insufficient coercivity, then a remanence of the data will exist.

Remanence is the measure of the existing magnetic field on the media; it is the residue that remains after an object is degaussed or written over. Data is still recoverable even when the remanence is small. While data remanence exists, there is no assurance of safe object reuse. Some degausses can destroy drives. The security professional should exercise caution when recommending or using degausses on media for reuse.

Software tools also exist that can provide object reuse assurance. These tools overwrite every sector of magnetic media with a random or predetermined bit pattern. Overwrite methods are effective for all forms of electronic media with the exception of read-only optical media. There is a drawback to using overwrite software. During normal write operations with magnetic media, the head of the drive moves back-and-forth across the media as data is written. The track of the head does not usually follow the exact path each time. The result is a miniscule amount of data remanence with each pass. With specialized equipment, it is possible to read data that has been overwritten.

To provide higher assurance in this case, it is necessary to overwrite each sector multiple times. Security practitioners should keep in mind that a one-time pass may be acceptable for noncritical information, but sensitive data should be overwritten with multiple passes. Overwrite software can also be used to clear the sectors within solid-state media such as USB thumb drives. It is suggested that physical destruction methods such as incineration or secure recycling should be considered for solid-state media that is no longer used.

The last form of preventing unauthorized access to sensitive data is media destruction. Shredding, burning, grinding, and pulverizing are common methods of physically destroying media. Degaussing can also be a form of media destruction. High-power degausses are so strong in some cases that they can literally bend and warp the platters in a hard drive.

Shredding and burning are effective destruction methods for non-rigid magnetic media. Indeed, some shredders are capable of shredding some rigid media such as an optical disk. This may be an effective alternative for any optical media containing nonsensitive information due to the residue size remaining after feeding the disk into the machine.

However, the residue size might be too large for media containing sensitive information. Alternatively, grinding and pulverizing are acceptable choices for rigid and solid-state media. Specialized devices are available for grinding the face of optical media that either sufficiently scratches the surface to render the media unreadable or actually grinds off the data layer of the disk. Several services also exist which will collect drives, destroy them on site if requested and provide certification of completion. It will be the responsibility of the security professional to help, select, and maintain the most appropriate solutions for media cleansing and disposal.

The following answers are incorrect:

Overwrite every sector of magnetic media with pattern of 1's and 0's-Less effective than degaussing provided magnetic media is not requiring to be reuse.
Format magnetic media Formatting magnetic media does not erase all data. Data can be recoverable after formatting using software tools.

Delete File allocation table-It will not erase all data. Data can be recoverable using software tools.

CISA review manual 2014 Page number 338

Official ISC2 guide to CISSP CBK 3rd Edition Page number 720.

QUESTION 484

IS management has decided to rewrite a legacy customer relations system using fourth generation languages (4GLs). Which of the following risks is MOST often associated with system development using 4GLs?

- A. Inadequate screen/report design facilities
- B. Complex programming language subsets
- C. Lack of portability across operating systems
- D. Inability to perform data intensive operations

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

4GLs are usually not suitable for data intensive operations. Instead, they are used mainly for graphic user interface (GUI) design or as simple query/report generators.

QUESTION 485

Which of the following would be the BEST method for ensuring that critical fields in a master record have been updated properly?

- A. Field checks
- B. Control totals
- C. Reasonableness checks
- D. A before-and-after maintenance report

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A before-and-after maintenance report is the best answer because a visual review would provide the most positive verification that updating was proper.

QUESTION 486

Which of the following is a dynamic analysis tool for the purpose of testing software modules?

- A. Blackbox test
- B. Desk checking
- C. Structured walk-through
- D. Design and code

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A blackbox test is a dynamic analysis tool for testing software modules. During the testing of software modules, a blackbox test works first in a cohesive manner as one single unit/entity, consisting of numerous modules and second, with the user data that flows across software modules. In some cases, this even drives the software behavior. In choices B, C and D, the software (design or code) remains static and someone

closely examines it by applying their mind, without actually activating the software. Therefore, these cannot be referred to as dynamic analysis tools.

QUESTION 487

Which of the following is MOST likely to result from a business process reengineering (BPR) Project?

- A. An increased number of people using technology
- B. Significant cost saving, through a reduction the complexity of information technology
- C. A weaker organizational structures and less accountability
- D. Increased information protection (IP) risk will increase

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A BPR project more often leads to an increased number of people using technology, and this would be a cause for concern. Incorrect answers:

B. As BPR is often technology oriented, and this technology is usually more complex and volatile than in the past, cost savings do not often materialize in this area.
D. There is no reason for IP to conflict with a BPR project, unless the project is not run properly.

QUESTION 488

Which of the following devices extends the network and has the capacity to store frames and act as a storage and forward device?

- A. Router

- B. Bridge
- C. Repeater
- D. Gateway

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A bridge connects two separate networks to form a logical network (e.g., joining an Ethernet and token network) and has the storage capacity to store frames and act as a storage and forward device. Bridges operate at the OSI data link layer by examining the media access control header of a data packet.

QUESTION 489

Which of the following is a benefit of using callback devices?

- A. Provide an audit trail
- B. Can be used in a switchboard environment
- C. Permit unlimited user mobility
- D. Allow call forwarding

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A callback feature hooks into the access control software and logs all authorized and unauthorized access attempts, permitting the follow-up and further review of potential breaches. Call forwarding (choice D) is a means of potentially bypassing callback control. By dialing through an authorized phone number from an unauthorized phone number, a perpetrator can gain computer access. This vulnerability can be controlled through callback systems that are available.

QUESTION 490

A call-back system requires that a user with an id and password call a remote server through a dial-up line, then the server disconnects and:

- A. dials back to the user machine based on the user id and password using a telephone number from its database.
- B. dials back to the user machine based on the user id and password using a telephone number provided by the user during this connection.
- C. waits for a redial back from the user machine for reconfirmation and then verifies the user id and password using its database.
- D. waits for a redial back from the user machine for reconfirmation and then verifies the user id and password using the sender's database.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A call-back system in a net centric environment would mean that a user with an id and password calls a remote server through a dial-up line first, and then the server disconnects and dials back to the user machine based on the user id and password using a telephone number from its database. Although the server can depend upon its own database, it cannot know the authenticity of the dialer when the user dials again. The server cannot depend upon the sender's database to dial back as the same could be manipulated.

QUESTION 491

Structured programming is BEST described as a technique that:

- A. provides knowledge of program functions to other programmers via peer reviews.
- B. reduces the maintenance time of programs by the use of small-scale program modules.
- C. makes the readable coding reflect as closely as possible the dynamic execution of the program.
- D. controls the coding and testing of the high-level functions of the program in the development process.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A characteristic of structured programming is smaller, workable units. Structured programming has evolved because smaller, workable units are easier to maintain. Structured programming is a style of programming which restricts the kinds of control structures. This limitation is not crippling. Any program can be written with allowed control structures. Structured programming is sometimes referred to as go-to-less programming, since a go-to statement is not allowed. This is perhaps the most well-known restriction of the style, since go-to statements were common at the time structured programming was becoming more popular. Statement labels also become unnecessary, except in languages where subroutines are identified by labels.

QUESTION 492

Which of the following data validation edits is effective in detecting transposition and transcription errors?

- A. Range check
- B. Check digit
- C. Validity check
- D. Duplicate check

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A check digit is a numeric value that is calculated mathematically and is appended to data to ensure that the original data have not been altered or an incorrect, but valid, value substituted. This control is effective in detecting transposition and transcription errors. A range check is checking data that matches a predetermined range of values. A validity check is programmed checking of the data validity in accordance with predetermined criteria. In a duplicate check, newer fresh transactions are matched to those previously entered to ensure that they are not already in the system.

QUESTION 493

An offsite information processing facility having electrical wiring, air conditioning and flooring, but no computer or communications equipment is a:

- A. cold site.
- B. warm site.

- C. dial-up site.
- D. duplicate processing facility.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A cold site is ready to receive equipment but does not offer any components at the site in advance of the need.

QUESTION 494

A number of system failures are occurring when corrections to previously detected errors are resubmitted for acceptance testing. This would indicate that the maintenance team is probably not adequately performing which of the following types of testing?

- A. Unit testing
- B. Integration testing
- C. Design walk-throughs
- D. Configuration management

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A common system maintenance problem is that errors are often corrected quickly (especially when deadlines are tight), units are tested by the programmer, and then transferred to the acceptance test area. This often results in system problems that should have been detected during integration or system testing. Integration testing aims at ensuring that the major components of the system interface correctly.

QUESTION 495

In an EDI process, the device which transmits and receives electronic documents is the:

- A. communications handler.
- B. EDI translator.
- C. application interface.
- D. EDI interface.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A communications handler transmits and receives electronic documents between trading partners and/or wide area networks (WANs).

QUESTION 496

The MOST significant level of effort for business continuity planning (BCP) generally is required during the:

- A. testing stage.
- B. evaluation stage.
- C. maintenance stage.
- D. early stages of planning.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Company.com in the early stages of a BCP will incur the most significant level of program development effort, which will level out as the BCP moves into maintenance, testing and evaluation stages. It is during the planning stage that an IS auditor will play an important role in obtaining senior management's commitment to resources and assignment of BCP responsibilities.

QUESTION 497

Which of the following network configuration options contains a direct link between any two host machines?

- A. Bus
- B. Ring
- C. Star
- D. Completely connected (mesh)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A completely connected mesh configuration creates a direct link between any two host machines.

QUESTION 498

Which of the following types of data validation editing checks is used to determine if a field contains data, and not zeros or blanks?

- A. Check digit
- B. Existence check
- C. Completeness check
- D. Reasonableness check

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A completeness check is used to determine if a field contains data and not zeros or blanks.

QUESTION 499

Which of the following tests is an IS auditor performing when a sample of programs is selected to determine if the source and object versions are the same?

- A. A substantive test of program library controls
- B. A compliance test of program library controls
- C. A compliance test of the program compiler controls
- D. A substantive test of the program compiler controls

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A compliance test determines if controls are operating as designed and are being applied in a manner that complies with management policies and procedures. For example, if the IS auditor is concerned whether program library controls are working properly, the IS auditor might select a sample of programs to determine if the source and object versions are the same. In other words, the broad objective of any compliance test is to provide auditors with reasonable assurance that a particular control on which the auditor plans to rely is operating as the auditor perceived it in the preliminary evaluation.

QUESTION 500

A data administrator is responsible for:

- A. maintaining database system software.
- B. defining data elements, data names and their relationship.
- C. developing physical database structures.
- D. developing data dictionary system software.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A data administrator is responsible for defining data elements, data names and their relationship. Choices A, C and D are functions of a database administrator (DBA)

QUESTION 501

A database administrator is responsible for:

- A. defining data ownership.
- B. establishing operational standards for the data dictionary.
- C. creating the logical and physical database.
- D. establishing ground rules for ensuring data integrity and security.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A database administrator is responsible for creating and controlling the logical and physical database. Defining data ownership resides with the head of the user department or top management if the data is common to the organization. IS management and the data administrator are responsible for establishing operational standards for the data dictionary. Establishing ground rules for ensuring data integrity and security in line with the corporate security policy is a function of the security administrator.

QUESTION 502

An IS auditor reviewing the key roles and responsibilities of the database administrator (DBA) is LEAST likely to expect the job description of the DBA to include:

- A. defining the conceptual schema.
- B. defining security and integrity checks.
- C. liaising with users in developing data model.
- D. mapping data model with the internal schema.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A DBA only in rare instances should be mapping data elements from the data model to the internal schema (physical data storage definitions). To do so would eliminate data independence for application systems. Mapping of the data model occurs with the conceptual schema since the conceptual schema represents the enterprise wide view of data within an organization and is the basis for deriving and end-user department data model.

QUESTION 503

To affix a digital signature to a message, the sender must first create a message digest by applying a cryptographic hashing algorithm against:

- A. the entire message and thereafter enciphering the message digest using the sender's private key.
- B. any arbitrary part of the message and thereafter enciphering the message digest using the sender's private key.
- C. the entire message and thereafter enciphering the message using the sender's private key.
- D. the entire message and thereafter enciphering the message along with the message digest using the sender's private key.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A digital signature is a cryptographic method that ensures data integrity, authentication of the message, and non-repudiation. To ensure these, the sender first creates a message digest by applying a cryptographic hashing algorithm against the entire message and thereafter enciphers the message digest using the sender's private key. A message digest is created by applying a cryptographic hashing algorithm against the entire message not on any arbitrary part of the message. After creating the message digest, only the message digest is enciphered using the sender's private key, not the message.

QUESTION 504

A sequence of bits appended to a digital document that is used to secure an e-mail sent through the Internet is called a:

- A. digest signature.
- B. electronic signature.
- C. digital signature.
- D. hash signature.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A digital signature through the private cryptographic key authenticates a transmission from a sender through the private cryptographic key. It is a string of bits that uniquely represent another string of bits, a digital document. An electronic signature refers to the string of bits that digitally represents a handwritten signature captured by a computer system when a human applies it on an electronic pen pad, connected to the system.

QUESTION 505

A critical function of a firewall is to act as a:

- A. special router that connects the Internet to a LAN.
- B. device for preventing authorized users from accessing the LAN.
- C. server used to connect authorized users to private trusted network resources.
- D. proxy server to increase the speed of access to authorized users.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A firewall is a set of related programs, located at a network gateway server, that protects the resources of a private network from users of other networks. An enterprise with an intranet that allows its workers access to the wider Internet installs a firewall to prevent outsiders from accessing its own private data resources and for controlling the outside resources to which its own users have access. Basically, a firewall, working closely with a router program, filters all network packets to determine whether or not to forward them toward their destination. A firewall includes or works with a proxy server that makes network requests on behalf of workstation users. A firewall is often installed in a specially designated computer separate from the rest of the network so no incoming request can get directed to private network resources.

QUESTION 506

Which of the following hardware devices relieves the central computer from performing network control, format conversion and message handling tasks?

- A. Spool
- B. Cluster controller
- C. Protocol converter
- D. Front end processor

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A front-end processor is a hardware device that connects all communication lines to a central computer to relieve the central computer.

QUESTION 507

The use of a GANTT chart can:

- A. aid in scheduling project tasks.
- B. determine project checkpoints.
- C. ensure documentation standards.
- D. direct the post-implementation review.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A GANTT chart is used in project control. It may aid in the identification of needed checkpoints but its primary use is in scheduling. It will not ensure the completion of documentation nor will it provide direction for the post- implementation review.

QUESTION 508

Which of the following translates e-mail formats from one network to another so that the message can travel through all the networks?

- A. Gateway
- B. Protocol converter
- C. Front-end communication processor
- D. Concentrator/multiplexor

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A gateway performs the job of translating e-mail formats from one network to another so messages can make their way through all the networks.

QUESTION 509

Which of the following BEST describes the necessary documentation for an enterprise product reengineering (EPR) software installation?

- A. Specific developments only
- B. Business requirements only

- C. All phases of the installation must be documented
- D. No need to develop a customer specific documentation

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A global enterprise product reengineering (EPR) software package can be applied to a business to replace, simplify and improve the quality of IS processing. Documentation is intended to help understand how, why and which solutions that have been selected and implemented, and therefore must be specific to the project. Documentation is also intended to support quality assurance and must be comprehensive.

QUESTION 510

A hub is a device that connects:

- A. two LANs using different protocols.
- B. a LAN with a WAN.
- C. a LAN with a metropolitan area network (MAN).
- D. two segments of a single LAN.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A hub is a device that connects two segments of a single LAN. A hub is a repeater. It provides transparent connectivity to users on all segments of the same LAN. It is a level 1 device.

QUESTION 511

A LAN administrator normally would be restricted from:

- A. having end-user responsibilities.
- B. reporting to the end-user manager.
- C. having programming responsibilities.
- D. being responsible for LAN security administration.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A LAN administrator should not have programming responsibilities but may have end-user responsibilities. The LAN administrator may report to the director of the IPF or, in a decentralized operation, to the end-user manager. In small organizations, the LAN administrator also may be responsible for security administration over the LAN.

QUESTION 512

Which of the following systems-based approaches would a financial processing company employ to monitor spending patterns to identify abnormal patterns and report them?

- A. A neural network
- B. Database management software
- C. Management information systems
- D. Computer assisted audit techniques

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A neural network will monitor and learn patterns, reporting exceptions for investigation.

QUESTION 513

A hardware control that helps to detect errors when data are communicated from one computer to another is known as a:

- A. duplicate check.
- B. table lookup.
- C. validity check.
- D. parity check.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A parity check will help to detect data errors when data are read from memory or communicated from one computer to another. A one-bit digit (either 0 or 1) is added to a data item to indicate whether the sum of that data item's bit is odd or even. When the parity bit disagrees with the sum of the other bits, an error report is generated.

QUESTION 514

For which of the following applications would rapid recovery be MOST crucial?

- A. Point-of-sale system
- B. Corporate planning
- C. Regulatory reporting
- D. Departmental chargeback

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A point-of-sale system is a critical online system that when inoperable will jeopardize the ability of Company.com to generate revenue and track inventory properly.

QUESTION 515

The initial step in establishing an information security program is the:

- A. development and implementation of an information security standards manual.
- B. performance of a comprehensive security control review by the IS auditor.
- C. adoption of a corporate information security policy statement.
- D. purchase of security access control software.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A policy statement reflects the intent and support provided by executive management for proper security and establishes a starting point for developing the security program.

QUESTION 516

A malicious code that changes itself with each file it infects is called a:

- A. logic bomb.
- B. stealth virus.
- C. trojan horse.
- D. polymorphic virus.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A polymorphic virus has the capability of changing its own code, enabling it to have many different variants. Since they have no consistent binary pattern, such viruses are hard to identify.

QUESTION 517

Which of the following is a continuity plan test that uses actual resources to simulate a system crash to cost-effectively obtain evidence about the plan's effectiveness?

- A. Paper test
- B. Post test
- C. Preparedness test
- D. Walk-through

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A preparedness test is a localized version of a full test, wherein resources are expended in the simulation of a system crash. This test is performed regularly on different aspects of the plan and can be a cost-effective way to gradually obtain evidence about the plan's effectiveness. It also provides a means to improve the plan in increments. A paper test is a walkthrough of the plan, involving major players, who attempt to determine what might happen in a particular type of service disruption in the plan's execution. A paper test usually precedes the preparedness test. A post-test is actually a test phase and is comprised of a group of activities, such as returning all resources to their proper place, disconnecting equipment, returning personnel and deleting all company data from third-party systems. A walkthrough is a test involving a simulated disaster situation that tests the preparedness and understanding of management and staff, rather than the actual resources.

QUESTION 518

An organization having a number of offices across a wide geographical area has developed a disaster recovery plan (DRP). Using actual resources, which of the following is the MOST cost-effective test of the DRP?

- A. Full operational test
- B. Preparedness test
- C. Paper test
- D. Regression test

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A preparedness test is performed by each local office/area to test the adequacy of the preparedness of local operations for the disaster recovery. A paper test is a structured walk-through of the disaster recovery plan and should be conducted before a preparedness test. A full operational test is conducted after the paper and preparedness test. A regression test is not a disaster recovery planning (DRP) test and is used in software maintenance.

QUESTION 519

The IS auditor learns that when equipment was brought into the data center by a vendor, the emergency power shutoff switch was accidentally pressed and the UPS was engaged. Which of the following audit recommendations should the IS auditor suggest?

- A. Relocate the shut off switch.
- B. Install protective covers.
- C. Escort visitors.
- D. Log environmental failures.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A protective cover over the switch would allow it to be accessible and visible, but would prevent accidental activation.

QUESTION 520

Company.com has contracted with an external consulting firm to implement a commercial financial system to replace its existing in-house developed system. In reviewing the proposed development approach, which of the following would be of GREATEST concern?

- A. Acceptance testing is to be managed by users.
- B. A quality plan is not part of the contracted deliverables.
- C. Not all business functions will be available on initial implementation.
- D. Prototyping is being used to confirm that the system meets business requirements.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A quality plan is an essential element of all projects. It is critical that the contracted supplier be required to produce such a plan. The quality plan for the proposed development contract should be comprehensive and encompass all phases of the development and include which business functions will be included and when. Acceptance is normally managed by the user area, since they must be satisfied that the new system will meet their requirements. If the system is large, a phased-in approach to implementing the application is a reasonable approach. Prototyping is a valid method of ensuring that the system will meet business

requirements.

QUESTION 521

In a public key infrastructure (PKI), the authority responsible for the identification and authentication of an applicant for a digital certificate (i.e., certificate subjects) is the:

- A. registration authority (RA).
- B. issuing certification authority (CA).
- C. subject CA.
- D. policy management authority.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A RA is an entity that is responsible for identification and authentication of certificate subjects, but the RA does not sign or issue certificates. The certificate subject usually interacts with the RA for completing the process of subscribing to the services of the certification authority in terms of getting identity validated with standard identification documents, as detailed in the certificate policies of the CA. In the context of a particular certificate, the issuing CA is the CA that issued the certificate. In the context of a particular CA certificate, the subject CA is the CA whose public key is certified in the certificate.

QUESTION 522

Which of the following is a data validation edit and control?

- A. Hash totals
- B. Reasonableness checks
- C. Online access controls
- D. Before and after image reporting

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A reasonableness check is a data validation edit and control, used to ensure that data conforms to predetermined criteria.

QUESTION 523

A control that detects transmission errors by appending calculated bits onto the end of each segment of data is known as a:

- A. reasonableness check.
- B. parity check.
- C. redundancy check.
- D. check digits.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A redundancy check detects transmission errors by appending calculated bits onto the end of each segment of data.

QUESTION 524

What is the primary objective of a control self-assessment (CSA) program?

- A. Enhancement of the audit responsibility
- B. Elimination of the audit responsibility
- C. Replacement of the audit responsibility
- D. Integrity of the audit responsibility

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Audit responsibility enhancement is an objective of a control self-assessment (CSA) program.

QUESTION 525

IS auditors are MOST likely to perform compliance tests of internal controls if, after their initial evaluation of the controls, they conclude that control risks are within the acceptable limits. True or false?

- A. True
- B. False

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

IS auditors are most likely to perform compliance tests of internal controls if, after their initial evaluation of the controls, they conclude that control risks are within the acceptable limits. Think of it this way: If any reliance is placed on internal controls, that reliance must be validated through compliance testing. High control risk results in little reliance on internal controls, which results in additional substantive testing.

QUESTION 526

As compared to understanding an organization's IT process from evidence directly collected, how valuable are prior audit reports as evidence?

- A. The same value.
- B. Greater value.
- C. Lesser value.
- D. Prior audit reports are not relevant.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Prior audit reports are considered of lesser value to an IS auditor attempting to gain an understanding of an organization's IT process than evidence directly collected.

QUESTION 527

The PRIMARY purpose of audit trails is to:

- A. improve response time for users.
- B. establish accountability and responsibility for processed transactions.
- C. improve the operational efficiency of the system.
- D. provide useful information to auditors who may wish to track transactions

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Enabling audit trails helps in establishing the accountability and responsibility of processed transactions by tracing transactions through the system. The objective of enabling software to provide audit trails is not to improve system efficiency, since it often involves additional processing which may in fact reduce response time for users. Enabling audit trails involves storage and thus occupies disk space.

QUESTION 528

How does the process of systems auditing benefit from using a risk-based approach to audit planning?

- A. Controls testing starts earlier.
- B. Auditing resources are allocated to the areas of highest concern.
- C. Auditing risk is reduced.
- D. Controls testing is more thorough.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Allocation of auditing resources to the areas of highest concern is a benefit of a risk-based approach to audit planning.

QUESTION 529

After an IS auditor has identified threats and potential impacts, the auditor should:

- A. Identify and evaluate the existing controls
- B. Conduct a business impact analysis (BIA)
- C. Report on existing controls
- D. Propose new controls

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

After an IS auditor has identified threats and potential impacts, the auditor should then identify and evaluate the existing controls.

QUESTION 530

The use of statistical sampling procedures helps minimize:

- A. Detection risk
- B. Business risk
- C. Controls risk
- D. Compliance risk

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The use of statistical sampling procedures helps minimize detection risk.

QUESTION 531

What type of risk results when an IS auditor uses an inadequate test procedure and concludes that material errors do not exist when errors actually exist?

- A. Business risk
- B. Detection risk
- C. Residual risk
- D. Inherent risk

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Detection risk results when an IS auditor uses an inadequate test procedure and concludes that material errors do not exist when errors actually exist.

QUESTION 532

A PRIMARY benefit derived by an organization employing control self-assessment (CSA) techniques is that CSA:

- A. can identify high-risk areas for detailed review.
- B. allows IS auditors to independently assess risk.
- C. can be used as a replacement for traditional audits.
- D. allows management to relinquish responsibility for control.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

CSA is predicated on the review of high-risk areas that either need immediate attention or a more thorough review at a later date. Choice B is incorrect, because CSA requires the involvement of auditors and line management. What occurs is that the internal audit function shifts some of the control monitoring responsibilities to the functional areas. Choice C is incorrect because CSA is not a replacement for traditional audits. CSA is not intended to replace audit's responsibilities, but to enhance them. Choice D is incorrect, because CSA does not allow management to relinquish its responsibility for control.

QUESTION 533

What type of approach to the development of organizational policies is often driven by risk assessment?

- A. Bottom-up
- B. Top-down
- C. Comprehensive
- D. Integrated

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A bottom-up approach to the development of organizational policies is often driven by risk assessment.

QUESTION 534

Who is accountable for maintaining appropriate security measures over information assets?

- A. Data and systems owners
- B. Data and systems users
- C. Data and systems custodians
- D. Data and systems auditors

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data and systems owners are accountable for maintaining appropriate security measures over information assets.

QUESTION 535

Proper segregation of duties prohibits a system analyst from performing quality-assurance functions. True or false?

- A. True
- B. False

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Proper segregation of duties prohibits a system analyst from performing quality-assurance functions.

QUESTION 536

What should an IS auditor do if he or she observes that project-approval procedures do not exist?

- A. Advise senior management to invest in project-management training for the staff
- B. Create project-approval procedures for future project implementations
- C. Assign project leaders

D. Recommend to management that formal approval procedures be adopted and documented

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If an IS auditor observes that project-approval procedures do not exist, the IS auditor should recommend to management that formal approval procedures be adopted and documented.

QUESTION 537

Who is ultimately accountable for the development of an IS security policy?

- A. The board of directors
- B. Middle management
- C. Security administrators
- D. Network administrators

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The board of directors is ultimately accountable for the development of an IS security policy.

QUESTION 538

Proper segregation of duties normally does not prohibit a LAN administrator from also having programming responsibilities. True or false?

- A. True
- B. False

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Proper segregation of duties normally prohibits a LAN administrator from also having programming responsibilities.

QUESTION 539

A core tenant of an IS strategy is that it must:

- A. Be inexpensive
- B. Be protected as sensitive confidential information
- C. Protect information confidentiality, integrity, and availability
- D. Support the business objectives of the organization

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Above all else, an IS strategy must support the business objectives of the organization.

QUESTION 540

Batch control reconciliation is a _____ (fill the blank) control for mitigating risk of

inadequate segregation of duties.

- A. Detective
- B. Corrective
- C. Preventative
- D. Compensatory

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Batch control reconciliations is a compensatory control for mitigating risk of inadequate segregation of duties.

QUESTION 541

Key verification is one of the best controls for ensuring that:

- A. Data is entered correctly
- B. Only authorized cryptographic keys are used
- C. Input is authorized
- D. Database indexing is performed properly

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Key verification is one of the best controls for ensuring that data is entered correctly.

QUESTION 542

If senior management is not committed to strategic planning, how likely is it that a company's implementation of IT will be successful?

- A. IT cannot be implemented if senior management is not committed to strategic planning.

- B. More likely.
- C. Less likely.
- D. Strategic planning does not affect the success of a company's implementation of IT.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A company's implementation of IT will be less likely to succeed if senior management is not committed to strategic planning.

QUESTION 543

Which of the following could lead to an unintentional loss of confidentiality?

- A. Lack of employee awareness of a company's information security policy
- B. Failure to comply with a company's information security policy
- C. A momentary lapse of reason
- D. Lack of security policy enforcement procedures

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Lack of employee awareness of a company's information security policy could lead to an unintentional loss of confidentiality.

QUESTION 544

What topology provides the greatest redundancy of routes and the greatest network fault tolerance?

- A. A star network topology
- B. A mesh network topology with packet forwarding enabled at each host
- C. A bus network topology
- D. A ring network topology

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A mesh network topology provides a point-to-point link between every network host. If each host is configured to route and forward communication, this topology provides the greatest redundancy of routes and the greatest network fault tolerance.

QUESTION 545

An IS auditor usually places more reliance on evidence directly collected. What is an example of such evidence?

- A. Evidence collected through personal observation
- B. Evidence collected through systems logs provided by the organization's security administration
- C. Evidence collected through surveys collected from internal staff
- D. Evidence collected through transaction reports provided by the organization's IT administration

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor usually places more reliance on evidence directly collected, such as through personal observation.

QUESTION 546

What kind of protocols does the OSI Transport Layer of the TCP/IP protocol suite provide to ensure reliable communication?

- A. Nonconnection-oriented protocols
- B. Connection-oriented protocols
- C. Session-oriented protocols
- D. Nonsession-oriented protocols

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The transport layer of the TCP/IP protocol suite provides for connection-oriented protocols to ensure reliable communication.

QUESTION 547

How is the time required for transaction processing review usually affected by properly implemented Electronic Data Interface (EDI)?

- A. EDI usually decreases the time necessary for review.
- B. EDI usually increases the time necessary for review.
- C. Cannot be determined.
- D. EDI does not affect the time necessary for review.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Electronic data interface (EDI) supports intervender communication while decreasing the time necessary for review because it is usually configured to readily identify errors requiring follow-up.

QUESTION 548

What would an IS auditor expect to find in the console log?

- A. Evidence of password spoofing
- B. System errors
- C. Evidence of data copy activities
- D. Evidence of password sharing

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor can expect to find system errors to be detailed in the console log.

QUESTION 549

Atomicity enforces data integrity by ensuring that a transaction is either completed in its entirety or not at all. Atomicity is part of the ACID test reference for transaction processing.

True or false?

- A. True
- B. False

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Atomicity enforces data integrity by ensuring that a transaction is either completed in its entirety or not at all. Atomicity is part of the ACID test reference for transaction processing.

QUESTION 550

Why does the IS auditor often review the system logs?

- A. To get evidence of password spoofing
- B. To get evidence of data copy activities
- C. To determine the existence of unauthorized access to data by a user or program
- D. To get evidence of password sharing

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When trying to determine the existence of unauthorized access to data by a user or program, the IS auditor will often review the system logs.

QUESTION 551

What is essential for the IS auditor to obtain a clear understanding of network management?

- A. Security administrator access to systems
- B. Systems logs of all hosts providing application services
- C. A graphical map of the network topology
- D. Administrator access to systems

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A graphical interface to the map of the network topology is essential for the IS auditor to obtain a clear understanding of network management.

QUESTION 552

How is risk affected if users have direct access to a database at the system level?

- A. Risk of unauthorized access increases, but risk of untraceable changes to the database decreases.
- B. Risk of unauthorized and untraceable changes to the database increases.
- C. Risk of unauthorized access decreases, but risk of untraceable changes to the database increases.
- D. Risk of unauthorized and untraceable changes to the database decreases.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If users have direct access to a database at the system level, risk of unauthorized and untraceable changes to the database increases.

QUESTION 553

What is the most common purpose of a virtual private network implementation?

- A. A virtual private network (VPN) helps to secure access between an enterprise and its partners when communicating over an otherwise unsecured channel such as the Internet.
- B. A virtual private network (VPN) helps to secure access between an enterprise and its partners when communicating over a dedicated T1 connection.
- C. A virtual private network (VPN) helps to secure access within an enterprise when communicating over a dedicated T1 connection between network segments within the same facility.
- D. A virtual private network (VPN) helps to secure access between an enterprise and its partners when communicating over a wireless connection.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A virtual private network (VPN) helps to secure access between an enterprise and its partners when communicating over an otherwise unsecured channel such as the Internet.

QUESTION 554

What benefit does using capacity-monitoring software to monitor usage patterns and trends provide to management?

- A. The software can dynamically readjust network traffic capabilities based upon current usage.
- B. The software produces nice reports that really impress management.
- C. It allows users to properly allocate resources and ensure continuous efficiency of operations.
- D. It allows management to properly allocate resources and ensure continuous efficiency of operations.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Using capacity-monitoring software to monitor usage patterns and trends enables management to properly allocate resources and ensure continuous efficiency of operations.

QUESTION 555

What can be very helpful to an IS auditor when determining the efficacy of a systems maintenance program?

- A. Network-monitoring software
- B. A system downtime log
- C. Administration activity reports
- D. Help-desk utilization trend reports

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A system downtime log can be very helpful to an IS auditor when determining the efficacy of a systems maintenance program.

QUESTION 556

What are used as a countermeasure for potential database corruption when two processes attempt to simultaneously edit or update the same information?

- A. Referential integrity controls
- B. Normalization controls
- C. Concurrency controls
- D. Run-to-run totals

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Concurrency controls are used as a countermeasure for potential database corruption when two processes attempt to simultaneously edit or update the same information.

QUESTION 557

What increases encryption overhead and cost the most?

- A. A long symmetric encryption key
- B. A long asymmetric encryption key
- C. A long Advance Encryption Standard (AES) key
- D. A long Data Encryption Standard (DES) key

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A long asymmetric encryption key (public key encryption) increases encryption overhead and cost. All other answers are single shared symmetric keys.

QUESTION 558

Which of the following best characterizes "worms"?

- A. Malicious programs that can run independently and can propagate without the aid of a carrier program such as email.
- B. Programming code errors that cause a program to repeatedly dump data
- C. Malicious programs that require the aid of a carrier program such as email
- D. Malicious programs that masquerade as common applications such as screensavers or macro-enabled Word documents

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Worms are malicious programs that can run independently and can propagate without the aid of a carrier program such as email.

QUESTION 559

What is an initial step in creating a proper firewall policy?

- A. Assigning access to users according to the principle of least privilege
- B. Determining appropriate firewall hardware and software

- C. Identifying network applications such as mail, web, or FTP servers
- D. Configuring firewall access rules

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Identifying network applications such as mail, web, or FTP servers to be externally accessed is an initial step in creating a proper firewall policy.

QUESTION 560

What type of cryptosystem is characterized by data being encrypted by the sender using the recipient's public key, and the data then being decrypted using the recipient's private key?

- A. With public-key encryption, or symmetric encryption
- B. With public-key encryption, or asymmetric encryption
- C. With shared-key encryption, or symmetric encryption
- D. With shared-key encryption, or asymmetric encryption

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

With public key encryption or asymmetric encryption, data is encrypted by the sender using the recipient's public key; the data is then decrypted using the recipient's private key.

QUESTION 561

How does the SSL network protocol provide confidentiality?

- A. Through symmetric encryption such as RSA
- B. Through asymmetric encryption such as Data Encryption Standard, or DES
- C. Through asymmetric encryption such as Advanced Encryption Standard, or AES
- D. Through symmetric encryption such as Data Encryption Standard, or DES

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The SSL protocol provides confidentiality through symmetric encryption such as Data Encryption Standard, or DES.

QUESTION 562

What are used as the framework for developing logical access controls?

- A. Information systems security policies
- B. Organizational security policies
- C. Access Control Lists (ACL)
- D. Organizational charts for identifying roles and responsibilities

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Information systems security policies are used as the framework for developing logical access controls.

QUESTION 563

Which of the following are effective controls for detecting duplicate transactions such as payments made or received?

- A. Concurrency controls
- B. Reasonableness checks
- C. Time stamps
- D. Referential integrity controls

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Time stamps are an effective control for detecting duplicate transactions such as payments made or received.

QUESTION 564

Which of the following is a good control for protecting confidential data residing on a PC?

- A. Personal firewall
- B. File encapsulation
- C. File encryption
- D. Host-based intrusion detection

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

File encryption is a good control for protecting confidential data residing on a PC.

QUESTION 565

Which of the following is a guiding best practice for implementing logical access controls?

- A. Implementing the Biba Integrity Model
- B. Access is granted on a least-privilege basis, per the organization's data owners
- C. Implementing the Take-Grant access control model
- D. Classifying data according to the subject's requirements

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Logical access controls should be reviewed to ensure that access is granted on a least-privilege basis, per the organization's data owners.

QUESTION 566

What does PKI use to provide some of the strongest overall control over data confidentiality, reliability, and integrity for Internet transactions?

- A. A combination of public-key cryptography and digital certificates and two-factor authentication
- B. A combination of public-key cryptography and two-factor authentication
- C. A combination of public-key cryptography and digital certificates
- D. A combination of digital certificates and two-factor authentication

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

PKI uses a combination of public-key cryptography and digital certificates to provide some of the strongest overall control over data confidentiality, reliability, and integrity for Internet transactions.

QUESTION 567

Which of the following do digital signatures provide?

- A. Authentication and integrity of data
- B. Authentication and confidentiality of data
- C. Confidentiality and integrity of data
- D. Authentication and availability of data

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary purpose of digital signatures is to provide authentication and integrity of data.

QUESTION 568

Regarding digital signature implementation, which of the following answers is correct?

- A. A digital signature is created by the sender to prove message integrity by encrypting the message with the sender's private key. Upon receiving the data, the recipient can decrypt the data using the sender's public key.
- B. A digital signature is created by the sender to prove message integrity by encrypting the message with the recipient's public key. Upon receiving the data, the recipient can decrypt the data using the recipient's public key.
- C. A digital signature is created by the sender to prove message integrity by initially using a hashing algorithm to produce a hash value or message digest from the entire message contents. Upon receiving the data, the recipient can independently create it.
- D. A digital signature is created by the sender to prove message integrity by encrypting the message with the sender's public key. Upon receiving the data, the recipient can decrypt the data using the recipient's private key.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A digital signature is created by the sender to prove message integrity by initially using a hashing algorithm to produce a hash value, or message digest, from the entire message contents. Upon receiving the data, the recipient can independently create its own message digest from the data for comparison and data integrity validation. Public and private are used to enforce confidentiality. Hashing algorithms are used to enforce integrity.

QUESTION 569

Which of the following would provide the highest degree of server access control?

- A. A mantrap-monitored entryway to the server room
- B. Host-based intrusion detection combined with CCTV
- C. Network-based intrusion detection
- D. A fingerprint scanner facilitating biometric access control

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A fingerprint scanner facilitating biometric access control can provide a very high degree of server access control.

QUESTION 570

What are often the primary safeguards for systems software and data?

- A. Administrative access controls
- B. Logical access controls
- C. Physical access controls

D. Detective access controls

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Logical access controls are often the primary safeguards for systems software and data.

QUESTION 571

Which of the following is often used as a detection and deterrent control against Internet attacks?

- A. Honeypots
- B. CCTV
- C. VPN
- D. VLAN

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Honeypots are often used as a detection and deterrent control against Internet attacks.

QUESTION 572

Which of the following BEST characterizes a mantrap or deadman door, which is used as a deterrent control for the vulnerability of piggybacking?

- A. A monitored double-doorway entry system
- B. A monitored turnstile entry system
- C. A monitored doorway entry system
- D. A one-way door that does not allow exit after entry

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A monitored double-doorway entry system, also referred to as a mantrap or deadman door, is used as a deterrent control for the vulnerability of piggybacking.

QUESTION 573

Which of the following is an effective method for controlling downloading of files via FTP?

- A. An application-layer gateway, or proxy firewall, but not stateful inspection firewalls
- B. An application-layer gateway, or proxy firewall
- C. A circuit-level gateway
- D. A first-generation packet-filtering firewall

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Application-layer gateways, or proxy firewalls, are an effective method for controlling downloading of files via FTP. Because FTP is an OSI application-layer protocol, the most effective firewall needs to be capable of inspecting through the application layer.

QUESTION 574

Which of the following provides the strongest authentication for physical access control?

- A. Sign-in logs
- B. Dynamic passwords
- C. Key verification
- D. Biometrics

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Biometrics can be used to provide excellent physical access control.

QUESTION 575

What is an effective countermeasure for the vulnerability of data entry operators potentially leaving their computers without logging off?

- A. Employee security awareness training
- B. Administrator alerts
- C. Screensaver passwords
- D. Close supervision

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Screensaver passwords are an effective control to implement as a countermeasure for the vulnerability of data entry operators potentially leaving their computers without logging off.

QUESTION 576

What can ISPs use to implement inbound traffic filtering as a control to identify IP packets transmitted from unauthorized sources?

- A. OSI Layer 2 switches with packet filtering enabled
- B. Virtual Private Networks
- C. Access Control Lists (ACL)
- D. Point-to-Point Tunneling Protocol

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

ISPs can use access control lists to implement inbound traffic filtering as a control to identify IP packets transmitted from unauthorized sources.

QUESTION 577

What is the key distinction between encryption and hashing algorithms?

- A. Hashing algorithms ensure data confidentiality.
- B. Hashing algorithms are irreversible.
- C. Encryption algorithms ensure data integrity.
- D. Encryption algorithms are not irreversible.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A key distinction between encryption and hashing algorithms is that hashing algorithms are irreversible.

QUESTION 578

Which of the following is BEST characterized by unauthorized modification of data before or during systems data entry?

- A. Data diddling
- B. Skimming
- C. Data corruption
- D. Salami attack

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data diddling involves modifying data before or during systems data entry.

QUESTION 579

Which of the following is used to evaluate biometric access controls?

- A. FAR
- B. EER
- C. ERR
- D. FRR

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When evaluating biometric access controls, a low equal error rate (EER) is preferred. EER is also called the crossover error rate (CER).

QUESTION 580

Who is ultimately responsible and accountable for reviewing user access to systems?

- A. Systems security administrators
- B. Data custodians
- C. Data owners
- D. Information systems auditors

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data owners are ultimately responsible and accountable for reviewing user access to systems.

QUESTION 581

Establishing data ownership is an important first step for which of the following processes?

- A. Assigning user access privileges
- B. Developing organizational security policies
- C. Creating roles and responsibilities
- D. Classifying data

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

To properly implement data classification, establishing data ownership is an important first step.

QUESTION 582

Which of the following is MOST critical during the business impact assessment phase of business continuity planning?

- A. End-user involvement
- B. Senior management involvement
- C. Security administration involvement
- D. IS auditing involvement

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

End-user involvement is critical during the business impact assessment phase of business continuity planning.

QUESTION 583

What type of BCP test uses actual resources to simulate a system crash and validate the plan's effectiveness?

- A. Paper
- B. Preparedness
- C. Walk-through
- D. Parallel

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Of the three major types of BCP tests (paper, walk-through, and preparedness), only the preparedness test uses actual resources to simulate a system crash and validate the plan's effectiveness.

QUESTION 584

Which of the following typically focuses on making alternative processes and resources available for transaction processing?

- A. Cold-site facilities
- B. Disaster recovery for networks
- C. Diverse processing
- D. Disaster recovery for systems

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Disaster recovery for systems typically focuses on making alternative processes and resources available for transaction processing.

QUESTION 585

Which type of major BCP test only requires representatives from each operational area to meet to review the plan?

- A. Parallel
- B. Preparedness
- C. Walk-thorough
- D. Paper

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Of the three major types of BCP tests (paper, walk-through, and preparedness), a walk-through test requires only that representatives from each operational area meet to review the plan.

QUESTION 586

What influences decisions regarding criticality of assets?

- A. The business criticality of the data to be protected
- B. Internal corporate politics
- C. The business criticality of the data to be protected, and the scope of the impact upon the organization as a whole
- D. The business impact analysis

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Criticality of assets is often influenced by the business criticality of the data to be protected and by the scope of the impact upon the organization as a whole. For example, the loss of a network backbone creates a much greater impact on the organization as a whole than the loss of data on a typical user's workstation.

QUESTION 587

Of the three major types of off-site processing facilities, what type is characterized by at least providing for electricity and HVAC?

- A. Cold site
- B. Alternate site
- C. Hot site
- D. Warm site

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Of the three major types of off-site processing facilities (hot, warm, and cold), a cold site is characterized by at least providing for electricity and HVAC. A warm site improves upon this by providing for redundant equipment and software that can be made operational within a short time.

QUESTION 588

With the objective of mitigating the risk and impact of a major business interruption, a disaster recovery plan should endeavor to reduce the length of recovery time necessary, as well as costs associated with recovery. Although DRP results in an increase of pre-and post-incident operational costs, the extra costs are more than offset by reduced recovery and business impact costs. True or false?

- A. True
- B. False

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

With the objective of mitigating the risk and impact of a major business interruption, a disaster- recovery plan should endeavor to reduce the length of recovery time necessary and the costs associated with recovery. Although DRP results in an increase of pre-and post-incident operational costs, the extra costs are more than offset by reduced recovery and business impact costs.

QUESTION 589

Of the three major types of off-site processing facilities, what type is often an acceptable solution for preparing for recovery of noncritical systems and data?

- A. Cold site
- B. Hot site
- C. Alternate site
- D. Warm site

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A cold site is often an acceptable solution for preparing for recovery of noncritical systems and data.

QUESTION 590

Any changes in systems assets, such as replacement of hardware, should be immediately recorded within the assets inventory of which of the following?

- A. IT strategic plan
- B. Business continuity plan
- C. Business impact analysis
- D. Incident response plan

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Any changes in systems assets, such as replacement of hardware, should be immediately recorded within the assets inventory of a business continuity plan.

QUESTION 591

Although BCP and DRP are often implemented and tested by middle management and end users, the ultimate responsibility and accountability for the plans remain with executive management, such as the _____. (fill-in-the-blank)

- A. Security administrator
- B. Systems auditor
- C. Board of directors
- D. Financial auditor

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Although BCP and DRP are often implemented and tested by middle management and end users, the ultimate responsibility and accountability for the plans remain with executive management, such as the board of directors.

QUESTION 592

Obtaining user approval of program changes is very effective for controlling application changes and maintenance. True or false?

- A. True
- B. False

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Obtaining user approval of program changes is very effective for controlling application changes and maintenance.

QUESTION 593

Library control software restricts source code to:

- A. Read-only access
- B. Write-only access
- C. Full access
- D. Read-write access

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Library control software restricts source code to read-only access.

QUESTION 594

When is regression testing used to determine whether new application changes have introduced any errors in the remaining unchanged code?

- A. In program development and change management
- B. In program feasibility studies
- C. In program development
- D. In change management

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Regression testing is used in program development and change management to determine whether new changes have introduced any errors in the remaining unchanged code.

QUESTION 595

What is often the most difficult part of initial efforts in application development?

- A. Configuring software
- B. Planning security
- C. Determining time and resource requirements
- D. Configuring hardware

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Determining time and resource requirements for an application-development project is often the most difficult part of initial efforts in application development.

QUESTION 596

What is a primary high-level goal for an auditor who is reviewing a system development project?

- A. To ensure that programming and processing environments are segregated
- B. To ensure that proper approval for the project has been obtained
- C. To ensure that business objectives are achieved
- D. To ensure that projects are monitored and administrated effectively

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A primary high-level goal for an auditor who is reviewing a systems- development project is to ensure that business objectives are achieved. This objective guides all other systems development objectives.

QUESTION 597

Whenever an application is modified, what should be tested to determine the full impact of the change?

- A. Interface systems with other applications or systems
- B. The entire program, including any interface systems with other applications or systems
- C. All programs, including interface systems with other applications or systems
- D. Mission-critical functions and any interface systems with other applications or systems

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Whenever an application is modified, the entire program, including any interface systems with other applications or systems, should be tested to determine the full impact of the change.

QUESTION 598

The quality of the metadata produced from a data warehouse is _____ in the warehouse's design.

- A. Often hard to determine because the data is derived from a heterogeneous data environment
- B. The most important consideration
- C. Independent of the quality of the warehoused databases
- D. Of secondary importance to data warehouse content

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The quality of the metadata produced from a data warehouse is the most important consideration in the warehouse's design.

QUESTION 599

Function Point Analysis (FPA) provides an estimate of the size of an information system based only on the number and complexity of a system's inputs and outputs. True or false?

- A. True
- B. False

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Function point analysis (FPA) provides an estimate of the size of an information system based on the number and complexity of a system's inputs, outputs, and files.

QUESTION 600

Who assumes ownership of a systems-development project and the resulting system?

- A. User management
- B. Project steering committee
- C. IT management
- D. Systems developers

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

User management assumes ownership of a systems-development project and the resulting system.

QUESTION 601

If an IS auditor observes that individual modules of a system perform correctly in development project tests, the auditor should inform management of the positive results and recommend further:

- A. Documentation development
- B. Comprehensive integration testing
- C. Full unit testing
- D. Full regression testing

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

If an IS auditor observes individual modules of a system perform correctly in development project tests, the auditor should inform management of the positive results and recommend further comprehensive integration testing.

QUESTION 602

When participating in a systems-development project, an IS auditor should focus on system controls rather than ensuring that adequate and complete documentation exists for all projects. True or false?

- A. True
- B. False

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When participating in a systems-development project, an IS auditor should also strive to ensure that adequate and complete documentation exists for all projects.

QUESTION 603

What is a reliable technique for estimating the scope and cost of a software-development project?

- A. Function point analysis (FPA)
- B. Feature point analysis (FPA)
- C. GANTT
- D. PERT

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A function point analysis (FPA) is a reliable technique for estimating the scope and cost of a software- development project.

QUESTION 604

Which of the following is a program evaluation review technique that considers different scenarios for planning and control projects?

- A. Function Point Analysis (FPA)
- B. GANTT
- C. Rapid Application Development (RAD)
- D. PERT

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

PERT is a program-evaluation review technique that considers different scenarios for planning and control projects.

QUESTION 605

Which of the following is the PRIMARY concern if a business continuity plan (BCP) is not based on a business impact analysis (BIA)?

- A. The critical systems were not identified, but all systems are covered in the BCP.
- B. The knowledge of key people within the organization was not considered in the BCP.
- C. The strategy of the BCP does not reflect estimated potential losses.
- D. Management was not involved in the early stages of the BCP.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 606

An e-commerce enterprise's disaster recovery (DR) site has 30% less processing capability than the primary site. Based on this information, which of the following presents the GREATEST risk?

- A. Network firewalls and database firewalls at the DR site do not provide high availability.
- B. No disaster recovery plan (DRP) testing has been performed during the last six months.
- C. The DR site is in a shared location that hosts multiple other enterprises.
- D. The DR site has not undergone testing to confirm its effectiveness.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 607

Which of the following BEST supports the risk assessment process to determine criticality of an asset?

- A. Threat assessment
- B. Residual risk analysis
- C. Vulnerability assessment
- D. Business impact analysis (BIA)

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 608

Which of the following is the MOST important prerequisite to performing an information security assessment?

- A. Reviewing the business impact analysis (BIA)
- B. Assessing threats and vulnerabilities
- C. Determining risk tolerance
- D. Classifying assets

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 609

To ensure appropriate control of information processed in IT systems, security safeguards should be based PRIMARILY on:

- A. established guidelines.
- B. overall IT capacity and operational constraints.
- C. efficient technical processing considerations.
- D. criteria consistent with classification levels.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 610

Which of the following is the MOST important factor when determining the frequency of information security risk reassessment?

- A. Audit findings
- B. Risk priority
- C. Mitigating controls
- D. Risk metrics

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 611

Which of the following is the MOST important consideration when designing information security architecture?

- A. Risk management parameters for the organization are defined.
- B. The existing threat landscape is monitored.
- C. The information security architecture is aligned with industry standards.
- D. The level of security supported is based on business decisions.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 612

Which of the following is a PRIMARY security responsibility of an information owner?

- A. Determining the controls associated with information classification
- B. Testing information classification controls
- C. Maintaining the integrity of data in the information systems
- D. Deciding what level of classification the information requires

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 613

Utilizing external resources for highly technical information security tasks allows an information security manager to:

- A. transfer business risk.
- B. distribute technology risk.
- C. outsource responsibility.
- D. leverage limited resources.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 614

The GREATEST benefit of choosing a private cloud over a public cloud would be:

- A. server protection.
- B. online service availability.
- C. containment of customer data.
- D. collection of data forensics.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 615

An organization is considering moving one of its critical business applications to a cloud hosting service. The cloud provider may not provide the same level of security for this application as the organization. Which of the following will provide the BEST information to help maintain the security posture?

- A. Risk assessment
- B. Cloud security strategy
- C. Vulnerability assessment
- D. Risk governance framework

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 616

Which is MOST important when contracting an external party to perform a penetration test?

- A. Obtain approval from IT management.
- B. Define the project scope.
- C. Increase the frequency of log reviews.
- D. Provide network documentation.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 617

A company has purchased a rival organization and is looking to integrate security strategies. Which of the following is the GREATEST issue to consider?

- A. The organizations have different risk appetites
- B. Differing security technologies

- C. Differing security skills within the organizations
- D. Confidential information could be leaked

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 618

An information security manager reads a media report of a new type of malware attack. Who should be notified FIRST?

- A. Security operations team
- B. Data owners
- C. Communications department
- D. Application owners

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 619

Which of the following is the MOST beneficial outcome of testing an incident response plan?

- A. The plan is enhanced to reflect the findings of the test.
- B. Test plan results are documented.
- C. Incident response time is improved.
- D. The response includes escalation to senior management.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 620

The selection of security controls is PRIMARILY linked to:

- A. risk appetite of the organization.
- B. regulatory requirements.
- C. business impact assessment.
- D. best practices of similar organizations.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 621

When an operating system is being hardened, it is MOST important for an information security manager to ensure that:

- A. default passwords are changed.
- B. anonymous access is removed.
- C. file access is restricted.
- D. system logs are activated.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 622

What should be the PRIMARY objective of conducting interviews with business unit managers when developing an information security strategy?

- A. Obtain information on department goals.
- B. Classify information assets.
- C. Identify data and system ownership.
- D. Determine information types.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 623

Which of the following will BEST provide an organization with ongoing assurance of the information security services provided by a cloud provider?

- A. Continuous monitoring of an information security risk profile
- B. Evaluating the provider's security incident response plan
- C. Requiring periodic self-assessment by the provider
- D. Ensuring the provider's roles and responsibilities are established

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 624

Meeting which of the following security objectives BEST ensures that information is protected against unauthorized modification?

- A. Availability
- B. Authenticity
- C. Confidentiality
- D. Integrity

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 625

Which of the following is MOST effective against system intrusions?

- A. Continuous monitoring
- B. Layered protection
- C. Penetration testing
- D. Two-factor authentication

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 626

Which of the following is MOST important to consider when developing a disaster recovery plan?

- A. Business continuity plan (BCP)
- B. Feasibility assessment
- C. Business impact analysis (BIA)
- D. Cost-benefit analysis

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 627

Within the confidentiality, integrity, and availability (CIA) triad, which of the following activities BEST supports the concept of integrity?

- A. Ensuring encryption for data in transit
- B. Implementing a data classification schema
- C. Utilizing a formal change management process
- D. Enforcing service level agreements (SLAs)

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 628

Which of the following is the MOST effective approach for integrating security into application development?

- A. Including security in user acceptance testing sign-off
- B. Performing vulnerability scans
- C. Developing security models in parallel
- D. Defining security requirements

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 629

Which of the following threats is prevented by using token-based authentication?

- A. Password sniffing attack on the network
- B. Session eavesdropping attack on the network
- C. Man-in-the-middle attack on the client
- D. Denial of service attack over the network

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 630

Which of the following tools BEST demonstrate the effectiveness of the information security program?

- A. A security balanced scorecard
- B. Management satisfaction surveys
- C. Risk heat map
- D. Key risk indicators (KRIs)

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 631

Which of the following is the PRIMARY reason social media has become a popular target for attack?

- A. The accessibility of social media from multiple locations
- B. The prevalence of strong perimeter protection
- C. The reduced effectiveness of access controls
- D. The element of trust created by social media

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 632

Which of the following is an example of a change to the external threat landscape?

- A. Organizational security standards have been modified.
- B. A commonly used encryption algorithm has been compromised.
- C. New legislation has been enacted in a region where the organization does business.
- D. Infrastructure changes to the organization have been implemented.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 633

Which of the following would MOST likely require a business continuity plan to be invoked?

- A. A distributed denial of service attack on an email server
- B. An unauthorized visitor discovered in the data center
- C. An epidemic preventing staff from performing job functions
- D. A hacker holding personally identifiable information hostage.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 634

Which of the following is the PRIMARY objective of a business impact analysis (BIA)?

- A. Define the recovery point objective (RPO).
- B. Analyze vulnerabilities.
- C. Confirm control effectiveness.
- D. Determine recovery priorities.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 635

Which of the following roles should be PRIMARILY responsible for assigning sensitivity levels to an organization's financial and payroll databases?

- A. Information security manager
- B. Data owner
- C. Systems administrator
- D. Database administrator

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 636

The PRIMARY benefit of integrating information security activities into change management processes is to:

- A. protect the organization from unauthorized changes.
- B. ensure required controls are included in changes.
- C. provide greater accountability for security-related changes in the business.
- D. protect the business from collusion and compliance threats.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 637

Which of the following provides the BEST indication that the information security program is in alignment with enterprise requirements?

- A. The security strategy is benchmarked with similar organizations.
- B. The information security manager reports to the chief executive officer.
- C. An IT governance committee is in place.
- D. Security strategy objectives are defined in business terms.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 638

Following a malicious security incident, an organization has decided to prosecute those responsible. Which of the following will BEST facilitate the forensic investigation?

- A. Identifying the affected environment
- B. Performing a backup of affected systems
- C. Determining the degree of loss
- D. Maintaining chain of custody

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 639

Which of the following would BEST justify spending for a compensating control?

- A. Peer benchmarking
- B. Risk analysis
- C. Threat analysis
- D. Vulnerability analysis

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 640

The PRIMARY purpose of vulnerability assessments is to:

- A. detect deficiencies that could lead to a system compromise.
- B. provide clear evidence that the system is sufficiently secure.
- C. test intrusion detection systems (IDS) and response procedures.
- D. determine the impact of potential threats.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 641

Calculation of the recovery time objective (RTO) is necessary to determine the:

- A. time required to restore files.
- B. annual loss expectancy (ALE).
- C. point of synchronization.
- D. priority of restoration.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 642

Which of the following metrics BEST evaluates the completeness of disaster-recovery preparations?

- A. Number of published applications-recovery plans

- B. Ratio of successful to unsuccessful tests
- C. Ratio of recovery-plan documents to total applications
- D. Ratio of tested application to total applications

Correct Answer: B
Explanation

Explanation/Reference:
 Section: Protection of Information Assets

QUESTION 643

An organization establishes an internal document collaboration site. To ensure data confidentiality of each project group, it is MOST important to:

- A. conduct a vulnerability assessment.
- B. enforce document life cycle management.
- C. prohibit remote access to the site.
- D. periodically recertify access rights.

Correct Answer: D
Explanation

Explanation/Reference:
 Section: Protection of Information Assets

QUESTION 644

Which of the following is MOST relevant for an information security manager to communicate to IT operations?

- A. The level of inherent risk
- B. Vulnerability assessments
- C. Threat assessments
- D. The level of exposure

Correct Answer: D
Explanation

Explanation/Reference:
 Section: Protection of Information Assets

QUESTION 645

The PRIMARY purpose of a periodic threat and risk assessment report to senior management is to communicate the:

- A. cost-benefit of security controls.
- B. status of the security posture.
- C. probability of future incidents.
- D. risk acceptance criteria.

Correct Answer: B
Explanation

Explanation/Reference:
 Section: Protection of Information Assets

QUESTION 646

Which of the following is the MOST important part of an incident response plan?

- A. Recovery point objective (RPO)
- B. Recovery time objective (RTO)
- C. Mean time to report (MTR)
- D. Business impact analysis (BIA)

Correct Answer: B
Explanation

Explanation/Reference:
 Section: Protection of Information Assets

QUESTION 647

If an IS auditor observes that an IS department fails to use formal documented methodologies, policies, and standards, what should the auditor do?

- A. Lack of IT documentation is not usually material to the controls tested in an IT audit.
- B. The auditor should at least document the informal standards and policies. Furthermore, the IS auditor should create formal documented policies to be implemented.
- C. The auditor should at least document the informal standards and policies, and test for a compliance. Furthermore, the IS auditor should recommend management that formal documented policies be developed and implemented.
- D. The auditor should at least document the informal standards and policies, and test for compliance. Furthermore, the IS auditor should create formal documented policies to be implemented.

Correct Answer: C
Explanation

Explanation/Reference:
 Section: Protection of Information Assets

If an IS auditor observes that an IS department fails to use formal documented methodologies, policies, and standards, the auditor should at least document the informal standards and policies, and test for compliance. Furthermore, the IS auditor should recommend to management that formal documented policies be developed and implemented.

QUESTION 648

What often results in project scope creep when functional requirements are not defined as well as they could be?

- A. Inadequate software baselining
- B. Insufficient strategic planning
- C. Inaccurate resource allocation
- D. Project delays

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Inadequate software baselining often results in project scope creep because functional requirements are not defined as well as they could be.

QUESTION 649

Fourth-Generation Languages (4GLs) are most appropriate for designing the application's graphical user interface (GUI). They are inappropriate for designing any intensive data- calculation procedures. True or false?

- A. True
- B. False

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Fourth-generation languages (4GLs) are most appropriate for designing the application's graphical user interface (GUI). They are inappropriate for designing any intensive data-calculation procedures.

QUESTION 650

Run-to-run totals can verify data through which stage(s) of application processing?

- A. Initial
- B. Various
- C. Final
- D. Output

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Run-to-run totals can verify data through various stages of application processing.

QUESTION 651

_____ (fill in the blank) is/are ultimately accountable for the functionality, reliability, and security within IT governance.

- A. Data custodians
- B. The board of directors and executive officers
- C. IT security administration
- D. Business unit managers

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The board of directors and executive officers are ultimately accountable for the functionality, reliability, and security within IT governance.

QUESTION 652

What can be used to help identify and investigate unauthorized transactions?

- A. Postmortem review
- B. Reasonableness checks
- C. Data-mining techniques
- D. Expert systems

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data-mining techniques can be used to help identify and investigate unauthorized transactions.

QUESTION 653

Network environments often add to the complexity of program-to-program communication, making the implementation and maintenance of application systems more difficult. True or false?

- A. True
- B. False

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Network environments often add to the complexity of program-to-program communication, making application systems implementation and maintenance more difficult.

QUESTION 654

_____ risk analysis is not always possible because the IS auditor is attempting to calculate risk using nonquantifiable threats and potential losses. In this event, a _____ risk assessment is more appropriate. Fill in the blanks.

- A. Quantitative; qualitative
- B. Qualitative; quantitative
- C. Residual; subjective
- D. Quantitative; subjective

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Quantitative risk analysis is not always possible because the IS auditor is attempting to calculate risk using nonquantifiable threats and potential losses. In this event, a qualitative risk assessment is more appropriate.

QUESTION 655

What must an IS auditor understand before performing an application audit?

- A. The potential business impact of application risks.
- B. Application risks must first be identified.
- C. Relative business processes.
- D. Relevant application risks.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor must first understand relative business processes before performing an application audit.

QUESTION 656

What is the first step in a business process re-engineering project?

- A. Identifying current business processes
- B. Forming a BPR steering committee
- C. Defining the scope of areas to be reviewed
- D. Reviewing the organizational strategic plan

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Defining the scope of areas to be reviewed is the first step in a business process re-engineering project.

QUESTION 657

When storing data archives off-site, what must be done with the data to ensure data completeness?

- A. The data must be normalized.
- B. The data must be validated.
- C. The data must be parallel-tested.
- D. The data must be synchronized.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When storing data archives off-site, data must be synchronized to ensure data completeness

QUESTION 658

Which of the following can help detect transmission errors by appending specially calculated bits onto the end of each segment of data?

- A. Redundancy check
- B. Completeness check
- C. Accuracy check
- D. Parity check

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A redundancy check can help detect transmission errors by appending specially calculated bits onto the end of each segment of data.

QUESTION 659

What is an edit check to determine whether a field contains valid data?

- A. Completeness check
- B. Accuracy check
- C. Redundancy check
- D. Reasonableness check

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A completeness check is an edit check to determine whether a field contains valid data.

QUESTION 660

A transaction journal provides the information necessary for detecting unauthorized _____ (fill in the blank) from a terminal.

- A. Deletion
- B. Input
- C. Access
- D. Duplication

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A transaction journal provides the information necessary for detecting unauthorized input from a terminal.

QUESTION 661

An intentional or unintentional disclosure of a password is likely to be evident within control logs. True or false?

- A. True
- B. False

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An intentional or unintentional disclosure of a password is not likely to be evident within control logs.

QUESTION 662

When are benchmarking partners identified within the benchmarking process?

- A. In the design stage
- B. In the testing stage
- C. In the research stage
- D. In the development stage

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Benchmarking partners are identified in the research stage of the benchmarking process.

QUESTION 663

A check digit is an effective edit check to:

- A. Detect data-transcription errors
- B. Detect data-transposition and transcription errors
- C. Detect data-transposition, transcription, and substitution errors
- D. Detect data-transposition errors

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A check digit is an effective edit check to detect data-transposition and transcription errors.

QUESTION 664

Parity bits are a control used to validate:

- A. Data authentication
- B. Data completeness
- C. Data source
- D. Data accuracy

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Parity bits are a control used to validate data completeness.

QUESTION 665

The traditional role of an IS auditor in a control self-assessment (CSA) should be that of a(n):

- A. Implementor
- B. Facilitator
- C. Developer
- D. Sponsor

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The traditional role of an IS auditor in a control self-assessment (CSA) should be that of a facilitator.

QUESTION 666

Which of the following would prevent accountability for an action performed, thus allowing nonrepudiation?

- A. Proper authentication
- B. Proper identification AND authentication
- C. Proper identification
- D. Proper identification, authentication, AND authorization

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If proper identification and authentication are not performed during access control, no accountability can exist for any action performed.

QUESTION 667

Which of the following is the MOST critical step in planning an audit?

- A. Implementing a prescribed auditing framework such as COBIT
- B. Identifying current controls
- C. Identifying high-risk audit targets
- D. Testing controls

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In planning an audit, the most critical step is identifying the areas of high risk.

QUESTION 668

To properly evaluate the collective effect of preventative, detective, or corrective controls within a process, an IS auditor should be aware of which of the following?

- A. The business objectives of the organization
- B. The effect of segregation of duties on internal controls
- C. The point at which controls are exercised as data flows through the system
- D. Organizational control policies

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When evaluating the collective effect of preventive, detective, or corrective controls within a process, an IS auditor should be aware of the point at which controls are exercised as data flows through the system.

QUESTION 669

What is the recommended initial step for an IS auditor to implement continuous-monitoring systems?

- A. Document existing internal controls
- B. Perform compliance testing on internal controls
- C. Establish a controls-monitoring steering committee
- D. Identify high-risk areas within the organization

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When implementing continuous-monitoring systems, an IS auditor's first step is to identify high-risk areas within the organization.

QUESTION 670

What type of risk is associated with authorized program exits (trap doors)?

- A. Business risk
- B. Audit risk
- C. Detective risk
- D. Inherent risk

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Inherent risk is associated with authorized program exits (trap doors).

QUESTION 671

Which of the following is best suited for searching for address field duplications?

- A. Text search forensic utility software
- B. Generalized audit software
- C. Productivity audit software
- D. Manual review

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Generalized audit software can be used to search for address field duplications.

QUESTION 672

Which of the following is of greatest concern to the IS auditor?

- A. Failure to report a successful attack on the network
- B. Failure to prevent a successful attack on the network
- C. Failure to recover from a successful attack on the network
- D. Failure to detect a successful attack on the network

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Lack of reporting of a successful attack on the network is a great concern to an IS auditor.

QUESTION 673

An integrated test facility is not considered a useful audit tool because it cannot compare processing output with independently calculated data. True or false?

- A. True
- B. False

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

An integrated test facility is considered a useful audit tool because it compares processing output with independently calculated data.

QUESTION 674

An advantage of a continuous audit approach is that it can improve system security when used in time-sharing environments that process a large number of transactions. True or false?

- A. True
- B. False

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

It is true that an advantage of a continuous audit approach is that it can improve system security when used in time-sharing environments that process a large number of transactions.

QUESTION 675

If an IS auditor finds evidence of risk involved in not implementing proper segregation of duties, such as having the security administrator perform an operations function, what is the auditor's primary responsibility?

- A. To advise senior management.
- B. To reassign job functions to eliminate potential fraud.
- C. To implement compensator controls.
- D. Segregation of duties is an administrative control not considered by an IS auditor.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

An IS auditor's primary responsibility is to advise senior management of the risk involved in not implementing proper segregation of duties, such as having the security administrator perform an operations function.

QUESTION 676

Who is responsible for implementing cost-effective controls in an automated system?

- A. Security policy administrators
- B. Business unit management
- C. Senior management
- D. Board of directors

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Business unit management is responsible for implementing cost-effective controls in an automated system.

QUESTION 677

Why does an IS auditor review an organization chart?

- A. To optimize the responsibilities and authority of individuals
- B. To control the responsibilities and authority of individuals
- C. To better understand the responsibilities and authority of individuals
- D. To identify project sponsors

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary reason an IS auditor reviews an organization chart is to better understand the responsibilities and authority of individuals.

QUESTION 678

Ensuring that security and control policies support business and IT objectives is a primary objective of:

- A. An IT security policies audit
- B. A processing audit
- C. A software audit
- D. A vulnerability assessment

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Ensuring that security and control policies support business and IT objectives is a primary objective of an IT security policies audit.

QUESTION 679

When auditing third-party service providers, an IS auditor should be concerned with which of the following?

- A. Ownership of the programs and files
- B. A statement of due care and confidentiality, and the capability for continued service of the service provider in the event of a disaster
- C. A statement of due care
- D. Ownership of programs and files, a statement of due care and confidentiality, and the capability for continued service of the service provider in the event of a disaster

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When auditing third-party service providers, an auditor should be concerned with ownership of programs and files, a statement of due care and confidentiality, and the capability for continued service of the service provider in the event of a disaster.

QUESTION 680

When performing an IS strategy audit, an IS auditor should review both short-term (one- year) and long-term (three-to five-year) IS strategies, interview appropriate corporate management personnel, and ensure that the external environment has been considered. The auditor should especially focus on procedures in an audit of IS strategy. True or false?

- A. True
- B. False

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When performing an IS strategy audit, an IS auditor should review both short-term (one-year) and long-term (three-to five-year) IS strategies, interview appropriate corporate management personnel, and ensure that the external environment has been considered.

QUESTION 681

What process allows IS management to determine whether the activities of the organization differ from the planned or expected levels?

- A. Business impact assessment
- B. Risk assessment
- C. IS assessment methods
- D. Key performance indicators (KPIs)

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

IS assessment methods allow IS management to determine whether the activities of the organization differ from the planned or expected levels.

QUESTION 682

When should reviewing an audit client's business plan be performed relative to reviewing an organization's IT strategic plan?

- A. Reviewing an audit client's business plan should be performed before reviewing an organization's IT strategic plan.
- B. Reviewing an audit client's business plan should be performed after reviewing an organization's IT strategic plan.
- C. Reviewing an audit client's business plan should be performed during the review of an organization's IT strategic plan.
- D. Reviewing an audit client's business plan should be performed without regard to an organization's IT strategic plan.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Reviewing an audit client's business plan should be performed before reviewing an organization's IT strategic plan.

QUESTION 683

Allowing application programmers to directly patch or change code in production programs increases risk of fraud. True or false?

- A. True

B. False

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Allowing application programmers to directly patch or change code in production programs increases risk of fraud.

QUESTION 684

Who should be responsible for network security operations?

- A. Business unit managers
- B. Security administrators
- C. Network administrators
- D. IS auditors

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Security administrators are usually responsible for network security operations.

QUESTION 685

Proper segregation of duties does not prohibit a quality control administrator from also being responsible for change control and problem management. True or false?

- A. True
- B. False

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Proper segregation of duties does not prohibit a quality-control administrator from also being responsible for change control and problem management.

QUESTION 686

What can be implemented to provide the highest level of protection from external attack?

- A. Layering perimeter network protection by configuring the firewall as a screened host in a screened subnet behind the bastion host
- B. Configuring the firewall as a screened host behind a router
- C. Configuring the firewall as the protecting bastion host
- D. Configuring two load-sharing firewalls facilitating VPN access from external hosts to internal hosts

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Layering perimeter network protection by configuring the firewall as a screened host in a screened subnet behind the bastion host provides a higher level of protection from external attack than all other answers.

QUESTION 687

The directory system of a database-management system describes:

- A. The access method to the data
- B. The location of data AND the access method
- C. The location of data
- D. Neither the location of data NOR the access method

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The directory system of a database-management system describes the location of data and the access method.

QUESTION 688

How is the risk of improper file access affected upon implementing a database system?

- A. Risk varies.
- B. Risk is reduced.
- C. Risk is not affected.
- D. Risk is increased.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Improper file access becomes a greater risk when implementing a database system.

QUESTION 689

In order to properly protect against unauthorized disclosure of sensitive data, how should hard disks be sanitized?

- A. The data should be deleted and overwritten with binary 0s.
- B. The data should be demagnetized.

- C. The data should be low-level formatted.
- D. The data should be deleted.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

To properly protect against unauthorized disclosure of sensitive data, hard disks should be demagnetized before disposal or release.

QUESTION 690

When reviewing print systems spooling, an IS auditor is MOST concerned with which of the following vulnerabilities?

- A. The potential for unauthorized deletion of report copies
- B. The potential for unauthorized modification of report copies
- C. The potential for unauthorized printing of report copies
- D. The potential for unauthorized editing of report copies

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When reviewing print systems spooling, an IS auditor is most concerned with the potential for unauthorized printing of report copies.

QUESTION 691

Why is the WAP gateway a component warranting critical concern and review for the IS auditor when auditing and testing controls enforcing message confidentiality?

- A. WAP is often configured by default settings and is thus insecure.
- B. WAP provides weak encryption for wireless traffic.
- C. WAP functions as a protocol-conversion gateway for wireless TLS to Internet SSL.
- D. WAP often interfaces critical IT systems.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Functioning as a protocol-conversion gateway for wireless TLS to Internet SSL, the WAP gateway is a

component warranting critical concern and review for the IS auditor when auditing and testing controls that enforce message confidentiality

QUESTION 692

Proper segregation of duties prevents a computer operator (user) from performing security administration duties. True or false?

- A. True
- B. False

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Proper segregation of duties prevents a computer operator (user) from performing security administration duties.

QUESTION 693

How do modems (modulation/demodulation) function to facilitate analog transmissions to enter a digital network?

- A. Modems convert analog transmissions to digital, and digital transmission to analog.
- B. Modems encapsulate analog transmissions within digital, and digital transmissions within analog.
- C. Modems convert digital transmissions to analog, and analog transmissions to digital.
- D. Modems encapsulate digital transmissions within analog, and analog transmissions within digital.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Modems (modulation/demodulation) convert analog transmissions to digital, and digital transmissions to analog, and are required for analog transmissions to enter a digital network.

QUESTION 694

Which of the following are effective in detecting fraud because they have the capability to consider a large number of variables when trying to resolve a problem?

- A. Expert systems
- B. Neural networks
- C. Integrated synchronized systems
- D. Multitasking applications

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Neural networks are effective in detecting fraud because they have the capability to consider a large number of variables when trying to resolve a problem.

QUESTION 695

What supports data transmission through split cable facilities or duplicate cable facilities?

- A. Diverse routing
- B. Dual routing
- C. Alternate routing
- D. Redundant routing

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Diverse routing supports data transmission through split cable facilities, or duplicate cable facilities.

QUESTION 696

What type(s) of firewalls provide(s) the greatest degree of protection and control because both firewall technologies inspect all seven OSI layers of network traffic?

- A. A first-generation packet-filtering firewall
- B. A circuit-level gateway
- C. An application-layer gateway, or proxy firewall, and stateful-inspection firewalls
- D. An application-layer gateway, or proxy firewall, but not stateful-inspection firewalls

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An application-layer gateway, or proxy firewall, and stateful-inspection firewalls provide the greatest degree of protection and control because both firewall technologies inspect all seven OSI layers of network traffic.

QUESTION 697

Which of the following can degrade network performance?

- A. Superfluous use of redundant load-sharing gateways
- B. Increasing traffic collisions due to host congestion by creating new collision domains
- C. Inefficient and superfluous use of network devices such as switches
- D. Inefficient and superfluous use of network devices such as hubs

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Inefficient and superfluous use of network devices such as hubs can degrade network performance.

QUESTION 698

Which of the following provide(s) near-immediate recoverability for time-sensitive systems and transaction processing?

- A. Automated electronic journaling and parallel processing
- B. Data mirroring and parallel processing
- C. Data mirroring
- D. Parallel processing

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data mirroring and parallel processing are both used to provide near-immediate recoverability for time-sensitive systems and transaction processing.

QUESTION 699

What is an effective control for granting temporary access to vendors and external support personnel?

- A. Creating user accounts that automatically expire by a predetermined date
- B. Creating permanent guest accounts for temporary use
- C. Creating user accounts that restrict logon access to certain hours of the day
- D. Creating a single shared vendor administrator account on the basis of least-privileged access

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Creating user accounts that automatically expire by a predetermined date is an effective control for granting temporary access to vendors and external support personnel.

QUESTION 700

Which of the following help(s) prevent an organization's systems from participating in a distributed denial-of-service (DDoS) attack?

- A. Inbound traffic filtering
- B. Using access control lists (ACLs) to restrict inbound connection attempts
- C. Outbound traffic filtering
- D. Recentralizing distributed systems

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Outbound traffic filtering can help prevent an organization's systems from participating in a distributed denial- of-service (DDoS) attack.

QUESTION 701

What is a common vulnerability, allowing denial-of-service attacks?

- A. Assigning access to users according to the principle of least privilege
- B. Lack of employee awareness of organizational security policies
- C. Improperly configured routers and router access lists
- D. Configuring firewall access rules

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Improperly configured routers and router access lists are a common vulnerability for denial-of- service attacks.

QUESTION 702

What are trojan horse programs?

- A. A common form of internal attack
- B. Malicious programs that require the aid of a carrier program such as email
- C. Malicious programs that can run independently and can propagate without the aid of a carrier program such as email
- D. A common form of Internet attack

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Trojan horse programs are a common form of Internet attack.

QUESTION 703

What is/are used to measure and ensure proper network capacity management and availability of services?

- A. Network performance-monitoring tools
- B. Network component redundancy
- C. Syslog reporting
- D. IT strategic planning

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Network performance-monitoring tools are used to measure and ensure proper network capacity management and availability of services.

QUESTION 704

What can be used to gather evidence of network attacks?

- A. Access control lists (ACL)
- B. Intrusion-detection systems (IDS)
- C. Syslog reporting
- D. Antivirus programs

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Intrusion-detection systems (IDS) are used to gather evidence of network attacks.

QUESTION 705

Which of the following is a passive attack method used by intruders to determine potential network vulnerabilities?

- A. Traffic analysis
- B. SYN flood
- C. Denial of service (DoS)
- D. Distributed denial of service (DoS)

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Traffic analysis is a passive attack method used by intruders to determine potential network vulnerabilities. All others are active attacks.

QUESTION 706

Which of the following fire-suppression methods is considered to be the most environmentally friendly?

- A. Halon gas
- B. Deluge sprinklers
- C. Dry-pipe sprinklers
- D. Wet-pipe sprinklers

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Although many methods of fire suppression exist, dry-pipe sprinklers are considered to be the most environmentally friendly.

QUESTION 707

What is a callback system?

- A. It is a remote-access system whereby the remote-access server immediately calls the user back at a predetermined number if the dial-in connection fails.
- B. It is a remote-access system whereby the user's application automatically redials the remote access server if the initial connection attempt fails.
- C. It is a remote-access control whereby the user initially connects to the network systems via dial-up access, only to have the initial connection terminated by the server, which then subsequently dials the user back at a predetermined number stored in the server's configuration database.
- D. It is a remote-access control whereby the user initially connects to the network systems via dial-up access, only to have the initial connection terminated by the server, which then subsequently allows the user to call back at an approved number for a limited period of time.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A callback system is a remote-access control whereby the user initially connects to the network systems via dial-up access, only to have the initial connection terminated by the server, which then subsequently dials the user back at a predetermined number stored in the server's configuration database.

QUESTION 708

What type of fire-suppression system suppresses fire via water that is released from a main valve to be delivered via a system of dry pipes installed throughout the facilities?

- A. A dry-pipe sprinkler system
- B. A deluge sprinkler system
- C. A wet-pipe system
- D. A halon sprinkler system

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A dry-pipe sprinkler system suppresses fire via water that is released from a main valve to be delivered via a system of dry pipes installed throughout the facilities.

QUESTION 709

Digital signatures require the sender to "sign" the data by encrypting the data with the sender's public key, to then be decrypted by the recipient using the recipient's private key.
True or false?

- A. False
- B. True

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Digital signatures require the sender to "sign" the data by encrypting the data with the sender's public key, to then be decrypted by the recipient using the sender's public key.

QUESTION 710

Which of the following provides the BEST single-factor authentication?

- A. Biometrics
- B. Password
- C. Token
- D. PIN

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Although biometrics provides only single-factor authentication, many consider it to be an excellent method for user authentication.

QUESTION 711

What is used to provide authentication of the website and can also be used to successfully authenticate keys used for data encryption?

- A. An organizational certificate
- B. A user certificate
- C. A website certificate
- D. Authenticode

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A website certificate is used to provide authentication of the website and can also be used to successfully authenticate keys used for data encryption.

QUESTION 712

What determines the strength of a secret key within a symmetric key cryptosystem?

- A. A combination of key length, degree of permutation, and the complexity of the data- encryption algorithm that uses the key
- B. A combination of key length, initial input vectors, and the complexity of the data- encryption algorithm that uses the key

- C. A combination of key length and the complexity of the data-encryption algorithm that uses the key
- D. Initial input vectors and the complexity of the data-encryption algorithm that uses the key

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The strength of a secret key within a symmetric key cryptosystem is determined by a combination of key length, initial input vectors, and the complexity of the data-encryption algorithm that uses the key.

QUESTION 713

What process is used to validate a subject's identity?

- A. Identification
- B. Nonrepudiation
- C. Authorization
- D. Authentication

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Authentication is used to validate a subject's identity.

QUESTION 714

What is often assured through table link verification and reference checks?

- A. Database integrity
- B. Database synchronization
- C. Database normalcy
- D. Database accuracy

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Database integrity is most often ensured through table link verification and reference checks.

QUESTION 715

Which of the following should an IS auditor review to determine user permissions that have been granted for a particular resource?

- A. Systems logs
- B. Access control lists (ACL)
- C. Application logs
- D. Error logs

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

IS auditors should review access-control lists (ACL) to determine user permissions that have been granted for a particular resource.

QUESTION 716

What should IS auditors always check when auditing password files?

- A. That deleting password files is protected
- B. That password files are encrypted
- C. That password files are not accessible over the network
- D. That password files are archived

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

IS auditors should always check to ensure that password files are encrypted.

QUESTION 717

Using the OSI reference model, what layer(s) is/are used to encrypt data?

- A. transport layer
- B. Session layer
- C. Session and transport layers
- D. Data link layer

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

User applications often encrypt and encapsulate data using protocols within the OSI session layer or farther down in the transport layer.

QUESTION 718

When should systems administrators first assess the impact of applications or systems patches?

- A. Within five business days following installation
- B. Prior to installation
- C. No sooner than five business days following installation
- D. Immediately following installation

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets
Systems administrators should always assess the impact of patches before installation.

QUESTION 719
Which of the following is the most fundamental step in preventing virus attacks?

- A. Adopting and communicating a comprehensive antivirus policy
- B. Implementing antivirus protection software on users' desktop computers
- C. Implementing antivirus content checking at all network-to-Internet gateways
- D. Inoculating systems with antivirus code

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets
Adopting and communicating a comprehensive antivirus policy is the most fundamental step in preventing virus attacks. All other antivirus prevention efforts rely upon decisions established and communicated via policy.

QUESTION 720
Which of the following is of greatest concern when performing an IS audit?

- A. Users' ability to directly modify the database
- B. Users' ability to submit queries to the database
- C. Users' ability to indirectly modify the database
- D. Users' ability to directly view the database

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets
A major IS audit concern is users' ability to directly modify the database.

QUESTION 721
What are intrusion-detection systems (IDS) primarily used for?

- A. To identify AND prevent intrusion attempts to a network
- B. To prevent intrusion attempts to a network
- C. Forensic incident response
- D. To identify intrusion attempts to a network

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets
Intrusion-detection systems (IDS) are used to identify intrusion attempts on a network.

QUESTION 722
Rather than simply reviewing the adequacy of access control, appropriateness of access policies, and effectiveness of safeguards and procedures, the IS auditor is more concerned with effectiveness and utilization of assets. True or false?

- A. True
- B. False

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets
Instead of simply reviewing the effectiveness and utilization of assets, an IS auditor is more concerned with adequate access control, appropriate access policies, and effectiveness of safeguards and procedures.

QUESTION 723
If a programmer has update access to a live system, IS auditors are more concerned with the programmer's ability to initiate or modify transactions and the ability to access production than with the programmer's ability to authorize transactions. True or false?

- A. True
- B. False

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets
If a programmer has update access to a live system, IS auditors are more concerned with the programmer's ability to initiate or modify transactions and the ability to access production than with the programmer's ability to authorize transactions.

QUESTION 724

Organizations should use off-site storage facilities to maintain _____ (fill in the blank) of current and critical information within backup files.

- A. Confidentiality
- B. Integrity
- C. Redundancy
- D. Concurrency

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Redundancy is the best answer because it provides both integrity and availability. Organizations should use off-site storage facilities to maintain redundancy of current and critical information within backup files.

QUESTION 725

The purpose of business continuity planning and disaster-recovery planning is to:

- A. Transfer the risk and impact of a business interruption or disaster
- B. Mitigate, or reduce, the risk and impact of a business interruption or disaster
- C. Accept the risk and impact of a business
- D. Eliminate the risk and impact of a business interruption or disaster

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary purpose of business continuity planning and disaster-recovery planning is to mitigate, or reduce, the risk and impact of a business interruption or disaster.

Total elimination of risk is impossible.

QUESTION 726

If a database is restored from information backed up before the last system image, which of the following is recommended?

- A. The system should be restarted after the last transaction.
- B. The system should be restarted before the last transaction.
- C. The system should be restarted at the first transaction.
- D. The system should be restarted on the last transaction.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If a database is restored from information backed up before the last system image, the system should be restarted before the last transaction because the final transaction must be reprocessed.

QUESTION 727

An off-site processing facility should be easily identifiable externally because easy identification helps ensure

smoother recovery. True or false?

- A. True
- B. False

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An off-site processing facility should not be easily identifiable externally because easy identification would create an additional vulnerability for sabotage.

QUESTION 728

Which of the following is the dominating objective of BCP and DRP?

- A. To protect human life
- B. To mitigate the risk and impact of a business interruption
- C. To eliminate the risk and impact of a business interruption
- D. To transfer the risk and impact of a business interruption

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Although the primary business objective of BCP and DRP is to mitigate the risk and impact of a business interruption, the dominating objective remains the protection of human life.

QUESTION 729

How can minimizing single points of failure or vulnerabilities of a common disaster best be controlled?

- A. By implementing redundant systems and applications onsite
- B. By geographically dispersing resources
- C. By retaining onsite data backup in fireproof vaults
- D. By preparing BCP and DRP documents for commonly identified disasters

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Minimizing single points of failure or vulnerabilities of a common disaster is mitigated by geographically dispersing resources.

QUESTION 730

Mitigating the risk and impact of a disaster or business interruption usually takes priority over transference of risk to a third party such as an insurer. True or false?

- A. True
- B. False

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Mitigating the risk and impact of a disaster or business interruption usually takes priority over transferring risk to a third party such as an insurer.

QUESTION 731

Off-site data storage should be kept synchronized when preparing for recovery of time- sensitive data such as that resulting from which of the following?

- A. Financial reporting
- B. Sales reporting
- C. Inventory reporting
- D. Transaction processing

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Off-site data storage should be kept synchronized when preparing for the recovery of timesensitive data such as that resulting from transaction processing.

QUESTION 732

What is an acceptable mechanism for extremely time-sensitive transaction processing?

- A. Off-site remote journaling
- B. Electronic vaulting
- C. Shadow file processing
- D. Storage area network

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Shadow file processing can be implemented as a recovery mechanism for extremely time- sensitive transaction processing.

QUESTION 733

Off-site data backup and storage should be geographically separated so as to _____ (fill in the blank) the risk of a widespread physical disaster such as a hurricane or earthquake.

- A. Accept
- B. Eliminate
- C. Transfer
- D. Mitigate

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Off-site data backup and storage should be geographically separated, to mitigate the risk of a widespread physical disaster such as a hurricane or an earthquake.

QUESTION 734

Why is a clause for requiring source code escrow in an application vendor agreement important?

- A. To segregate systems development and live environments
- B. To protect the organization from copyright disputes
- C. To ensure that sufficient code is available when needed
- D. To ensure that the source code remains available even if the application vendor goes out of business

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A clause for requiring source code escrow in an application vendor agreement is important to ensure that the source code remains available even if the application vendor goes out of business.

QUESTION 735

What uses questionnaires to lead the user through a series of choices to reach a conclusion?

- A. Logic trees
- B. Decision trees
- C. Decision algorithms

D. Logic algorithms

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Decision trees use questionnaires to lead the user through a series of choices to reach a conclusion.

QUESTION 736

What protects an application purchaser's ability to fix or change an application in case the application vendor goes out of business?

- A. Assigning copyright to the organization
- B. Program back doors
- C. Source code escrow
- D. Internal programming expertise

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Source code escrow protects an application purchaser's ability to fix or change an application in case the application vendor goes out of business.

QUESTION 737

Who is ultimately responsible for providing requirement specifications to the software- development team?

- A. The project sponsor
- B. The project members
- C. The project leader
- D. The project steering committee

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The project sponsor is ultimately responsible for providing requirement specifications to the software- development team.

QUESTION 738

What should regression testing use to obtain accurate conclusions regarding the effects of changes or corrections to a program, and ensuring that those changes and corrections have not introduced new errors?

- A. Contrived data
- B. Independently created data
- C. Live data
- D. Data from previous tests

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Regression testing should use data from previous tests to obtain accurate conclusions regarding the effects of changes or corrections to a program, and ensuring that those changes and corrections have not introduced new errors.

QUESTION 739

An IS auditor should carefully review the functional requirements in a system-development project to ensure that the project is designed to:

- A. Meet business objectives
- B. Enforce data security
- C. Be culturally feasible
- D. Be financially feasible

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor should carefully review the functional requirements in a systems-development project to ensure that the project is designed to meet business objectives.

QUESTION 740

Which of the following processes are performed during the design phase of the systems development life cycle (SDLC) model?

- A. Develop test plans.
- B. Baseline procedures to prevent scope creep.
- C. Define the need that requires resolution, and map to the major requirements of the solution.
- D. Program and test the new system. The tests verify and validate what has been developed.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Procedures to prevent scope creep are baselined in the design phase of the systems- development life cycle (SDLC) model.

QUESTION 741

When should application controls be considered within the system-development process?

- A. After application unit testing
- B. After application module testing
- C. After applications systems testing
- D. As early as possible, even in the development of the project's functional specifications

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Application controls should be considered as early as possible in the system- development process, even in the development of the project's functional specifications.

QUESTION 742

What is used to develop strategically important systems faster, reduce development costs, and still maintain high quality?

- A. Rapid application development (RAD)
- B. GANTT
- C. PERT
- D. Decision trees

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Rapid application development (RAD) is used to develop strategically important systems faster, reduce development costs, and still maintain high quality.

QUESTION 743

Test and development environments should be separated. True or false?

- A. True
- B. False

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Test and development environments should be separated, to control the stability of the test environment.

QUESTION 744

What kind of testing should programmers perform following any changes to an application or system?

- A. Unit, module, and full regression testing
- B. Module testing
- C. Unit testing
- D. Regression testing

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Programmers should perform unit, module, and full regression testing following any changes to an application or system.

QUESTION 745

Which of the following uses a prototype that can be updated continually to meet changing user or business requirements?

- A. PERT
- B. Rapid application development (RAD)
- C. Function point analysis (FPA)
- D. GANTT

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Rapid application development (RAD) uses a prototype that can be updated continually to meet changing user or business requirements.

QUESTION 746

What is the most common reason for information systems to fail to meet the needs of users?

- A. Lack of funding
- B. Inadequate user participation during system requirements definition
- C. Inadequate senior management participation during system requirements definition
- D. Poor IT strategic planning

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Inadequate user participation during system requirements definition is the most common reason for information systems to fail to meet the needs of users.

QUESTION 747

Who is responsible for the overall direction, costs, and timetables for systems-development projects?

- A. The project sponsor
- B. The project steering committee
- C. Senior management
- D. The project team leader

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The project steering committee is responsible for the overall direction, costs, and timetables for systems- development projects.

QUESTION 748

When should plans for testing for user acceptance be prepared?

- A. In the requirements definition phase of the systems-development project
- B. In the feasibility phase of the systems-development project
- C. In the design phase of the systems-development project
- D. In the development phase of the systems-development project

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Plans for testing for user acceptance are usually prepared in the requirements definition phase of the systems- development project.

QUESTION 749

Above almost all other concerns, what often results in the greatest negative impact on the implementation of new application software?

- A. Failing to perform user acceptance testing
- B. Lack of user training for the new system
- C. Lack of software documentation and run manuals
- D. Insufficient unit, module, and systems testing

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Above almost all other concerns, failing to perform user acceptance testing often results in the greatest negative impact on the implementation of new application software.

QUESTION 750

Input/output controls should be implemented for which applications in an integrated systems environment?

- A. The receiving application
- B. The sending application
- C. Both the sending and receiving applications
- D. Output on the sending application and input on the receiving application

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Input/output controls should be implemented for both the sending and receiving applications in an integrated systems environment

QUESTION 751

Authentication techniques for sending and receiving data between EDI systems is crucial to prevent which of the following?

- A. Unsynchronized transactions
- B. Unauthorized transactions
- C. Inaccurate transactions
- D. Incomplete transactions

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Authentication techniques for sending and receiving data between EDI systems are crucial to prevent unauthorized transactions.

QUESTION 752

After identifying potential security vulnerabilities, what should be the IS auditor's next step?

- A. To evaluate potential countermeasures and compensatory controls
- B. To implement effective countermeasures and compensatory controls
- C. To perform a business impact analysis of the threats that would exploit the vulnerabilities
- D. To immediately advise senior management of the findings

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

After identifying potential security vulnerabilities, the IS auditor's next step is to perform a business impact analysis of the threats that would exploit the vulnerabilities.

QUESTION 753

What is the primary security concern for EDI environments?

- A. Transaction authentication
- B. Transaction completeness
- C. Transaction accuracy
- D. Transaction authorization

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Transaction authorization is the primary security concern for EDI environments.

QUESTION 754

Which of the following exploit vulnerabilities to cause loss or damage to the organization and its assets?

- A. Exposures
- B. Threats
- C. Hazards
- D. Insufficient controls

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Threats exploit vulnerabilities to cause loss or damage to the organization and its assets.

QUESTION 755

Business process re-engineering often results in _____ automation, which results in _____ number of people using technology. Fill in the blanks.

- A. Increased; a greater
- B. Increased; a fewer
- C. Less; a fewer
- D. Increased; the same

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Business process re-engineering often results in increased automation, which results in a greater number of people using technology.

QUESTION 756

Whenever business processes have been re-engineered, the IS auditor attempts to identify and quantify the impact of any controls that might have been removed, or controls that might not work as effectively after business process changes. True or false?

- A. True
- B. False

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Whenever business processes have been re-engineered, the IS auditor should attempt to identify and quantify the impact of any controls that might have been removed, or controls that might not work as effectively after business process changes.

QUESTION 757

When should an application-level edit check to verify that availability of funds was completed at the electronic funds transfer (EFT) interface?

- A. Before transaction completion
- B. Immediately after an EFT is initiated
- C. During run-to-run total testing
- D. Before an EFT is initiated

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An application-level edit check to verify availability of funds should be completed at the electronic funds transfer (EFT) interface before an EFT is initiated.

QUESTION 758

_____ should be implemented as early as data preparation to support data integrity at the earliest point possible.

- A. Control totals
- B. Authentication controls
- C. Parity bits
- D. Authorization controls

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Control totals should be implemented as early as data preparation to support data integrity at the earliest point possible.

QUESTION 759

What is used as a control to detect loss, corruption, or duplication of data?

- A. Redundancy check
- B. Reasonableness check
- C. Hash totals
- D. Accuracy check

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Hash totals are used as a control to detect loss, corruption, or duplication of data.

QUESTION 760

Data edits are implemented before processing and are considered which of the following?

- A. Deterrent integrity controls
- B. Detective integrity controls
- C. Corrective integrity controls
- D. Preventative integrity controls

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Data edits are implemented before processing and are considered preventive integrity controls.

QUESTION 761

Processing controls ensure that data is accurate and complete, and is processed only through which of the following?

- A. Documented routines
- B. Authorized routines
- C. Accepted routines
- D. Approved routines

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Processing controls ensure that data is accurate and complete, and is processed only through authorized routines.

QUESTION 762

What is a data validation edit control that matches input data to an occurrence rate? Choose the BEST answer.

- A. Accuracy check
- B. Completeness check
- C. Reasonableness check
- D. Redundancy check

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A reasonableness check is a data validation edit control that matches input data to an occurrence rate.

QUESTION 763

Database snapshots can provide an excellent audit trail for an IS auditor. True or false?

- A. True
- B. False

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Database snapshots can provide an excellent audit trail for an IS auditor.

QUESTION 764

An IS auditor is using a statistical sample to inventory the tape library. What type of test would this be considered?

- A. Substantive
- B. Compliance
- C. Integrated
- D. Continuous audit

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Using a statistical sample to inventory the tape library is an example of a substantive test.

QUESTION 765

An IS auditor is reviewing access to an application to determine whether the 10 most recent "new user" forms were correctly authorized. This is an example of:

- A. variable sampling.
- B. substantive testing.
- C. compliance testing.
- D. stop-or-go sampling.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Compliance testing determines whether controls are being applied in compliance with policy. This includes tests to determine whether new accounts were appropriately authorized. Variable sampling is used to estimate numerical values, such as dollar values. Substantive testing substantiates the integrity of actual processing; such as balances on financial statements. The development of substantive tests is often dependent on the

outcome of compliance tests. If compliance tests indicate that there are adequate internal controls, then substantive tests can be minimized. Stop-or-go sampling allows a test to be stopped as early as possible and is not appropriate for checking whether procedures have been followed.

QUESTION 766

The decisions and actions of an IS auditor are MOST likely to affect which of the following risks?

- A. Inherent
- B. Detection
- C. Control
- D. Business

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Detection risks are directly affected by the auditor's selection of audit procedures and techniques. Inherent risks are not usually affected by an IS auditor. Control risks are controlled by the actions of the company's management. Business risks are not affected by an IS auditor.

QUESTION 767

Overall business risk for a particular threat can be expressed as:

- A. a product of the probability and magnitude of the impact if a threat successfully exploits a vulnerability.
- B. the magnitude of the impact should a threat source successfully exploit the vulnerability.
- C. the likelihood of a given threat source exploiting a given vulnerability.
- D. the collective judgment of the risk assessment team.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Choice A takes into consideration the likelihood and magnitude of the impact and provides the best measure of the risk to an asset. Choice B provides only the likelihood of a threat exploiting a vulnerability in the asset but does not provide the magnitude of the possible damage to the asset. Similarly, choice C considers only the magnitude of the damage and not the possibility of a threat exploiting a vulnerability. Choice D defines the risk on an arbitrary basis and is not suitable for a scientific risk management process.

QUESTION 768

Which of the following is a substantive test?

- A. Checking a list of exception reports
- B. Ensuring approval for parameter changes
- C. Using a statistical sample to inventory the tape library
- D. Reviewing password history reports

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A substantive test confirms the integrity of actual processing. A substantive test would determine if the tape library records are stated correctly. A compliance test determines if controls are being applied in a manner that is consistent with management policies and procedures. Checking the authorization of exception reports, reviewing authorization for changing parameters and reviewing password history reports are all compliance tests.

QUESTION 769

Which of the following is a benefit of a risk-based approach to audit planning? Audit:

- A. scheduling may be performed months in advance.
- B. budgets are more likely to be met by the IS audit staff.
- C. staff will be exposed to a variety of technologies.
- D. resources are allocated to the areas of highest concern

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The risk-based approach is designed to ensure audit time is spent on the areas of highest risk. The development of an audit schedule is not addressed by a risk-based approach. Audit schedules may be prepared months in advance using various scheduling methods. A risk approach does not have a direct correlation to the audit staff meeting time budgets on a particular audit, nor does it necessarily mean a wider variety of audits will be performed in a given year.

QUESTION 770

An audit charter should:

- A. be dynamic and change often to coincide with the changing nature of technology and the audit profession.
- B. clearly state audit objectives for, and the delegation of, authority to the maintenance and review of internal controls.
- C. document the audit procedures designed to achieve the planned audit objectives.
- D. outline the overall authority, scope and responsibilities of the audit function.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An audit charter should state management's objectives for and delegation of authority to IS audit. This charter should not significantly change over time and should be approved at the highest level of management. An audit charter would not be at a detailed level and, therefore, would not include specific audit objectives or procedures.

QUESTION 771

The MAJOR advantage of the risk assessment approach over the baseline approach to information security management is that it ensures:

- A. information assets are overprotected.
- B. a basic level of protection is applied regardless of asset value.
- C. appropriate levels of protection are applied to information assets.
- D. an equal proportion of resources are devoted to protecting all information assets.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Full risk assessment determines the level of protection most appropriate to a given level of risk, while the baseline approach merely applies a standard set of protection regardless of risk. There is a cost advantage in not overprotecting information. However, an even bigger advantage is making sure that no information assets are over- or under protected. The risk assessment approach will ensure an appropriate level of protection is applied, commensurate with the level of risk and asset value and, therefore, considering asset value. The baseline approach does not allow more resources to be directed toward the assets at greater risk, rather than equally directing resources to all assets.

QUESTION 772

Which of the following sampling methods is MOST useful when testing for compliance?

- A. Attribute sampling
- B. Variable sampling
- C. Stratified mean per unit
- D. Difference estimation

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Attribute sampling is the primary sampling method used for compliance testing. Attribute sampling is a sampling model that is used to estimate the rate of occurrence of a specific quality (attribute) in a population and is used in compliance testing to confirm whether the quality exists. The other choices are used in substantive testing, which involves testing of details or quantity.

QUESTION 773

Which of the following is the MOST likely reason why e-mail systems have become a useful source of evidence for litigation?

- A. Multiple cycles of backup files remain available.
- B. Access controls establish accountability for e-mail activity.
- C. Data classification regulates what information should be communicated via e-mail.
- D. Within the enterprise, a clear policy for using e-mail ensures that evidence is available.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Backup files containing documents that supposedly have been deleted could be recovered from these files. Access controls may help establish accountability for the issuance of a particular document, but this does not provide evidence of the e-mail. Data classification standards may be in place with regards to what should be communicated via e-mail, but the creation of the policy does not provide the information required for litigation purposes.

QUESTION 774

An IS auditor is assigned to perform a post implementation review of an application system. Which of the following situations may have impaired the independence of the IS auditor? The IS auditor:

- A. implemented a specific control during the development of the application system.
- B. designed an embedded audit module exclusively for auditing the application system.
- C. participated as a member of the application system project team, but did not have operational responsibilities.
- D. provided consulting advice concerning application system best practices.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Independence may be impaired if an IS auditor is, or has been, actively involved in the development, acquisition and implementation of the application system. Choices B and C are situations that do not impair an IS auditor's independence. Choice D is incorrect because an IS auditor's independence is not impaired by providing advice on known best practices.

QUESTION 775

The PRIMARY advantage of a continuous audit approach is that it:

- A. does not require an IS auditor to collect evidence on system reliability while processing is taking place.
- B. requires the IS auditor to review and follow up immediately on all information collected.
- C. can improve system security when used in time-sharing environments that process a large number of transactions.
- D. does not depend on the complexity of an organization's computer systems.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The use of continuous auditing techniques can improve system security when used in time-sharing environments that process a large number of transactions, but leave a scarce paper trail. Choice A is incorrect since the continuous audit approach often does require an IS auditor to collect evidence on system reliability while processing is taking place. Choice B is incorrect since an IS auditor normally would review and follow up only on material deficiencies or errors detected. Choice D is incorrect since the use of continuous audit techniques depends on the complexity of an organization's computer systems.

QUESTION 776

When developing a risk-based audit strategy, an IS auditor conduct a risk assessment to ensure that:

- A. controls needed to mitigate risks are in place.
- B. vulnerabilities and threats are identified.
- C. audit risks are considered.
- D. a gap analysis is appropriate.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In developing a risk-based audit strategy, it is critical that the risks and vulnerabilities be understood. This will determine the areas to be audited and the extent of coverage.

Understanding whether appropriate controls required to mitigate risks are in place is a resultant effect of an audit. Audit risks are inherent aspects of auditing, are directly related to the audit process and are not relevant to the risk analysis of the environment to be audited. A gap analysis would normally be done to compare the actual state to an expected or desirable state.

QUESTION 777

To ensure that audit resources deliver the best value to the organization, the FIRST step would be to:

- A. schedule the audits and monitor the time spent on each audit.
- B. train the IS audit staff on current technology used in the company.
- C. develop the audit plan on the basis of a detailed risk assessment.
- D. monitor progress of audits and initiate cost control measures.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Monitoring the time (choice A) and audit programs (choice D), as well as adequate training (choice B), will improve the IS audit staff's productivity (efficiency and performance), but that which delivers value to the organization are the resources and efforts being dedicated to, and focused on, the higher-risk areas.

QUESTION 778

An organization's IS audit charter should specify the:

- A. short- and long-term plans for IS audit engagements
- B. objectives and scope of IS audit engagements.
- C. detailed training plan for the IS audit staff.
- D. role of the IS audit function.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS audit charter establishes the role of the information systems audit function. The charter should describe the overall authority, scope, and responsibilities of the audit function. It should be approved by the highest level of management and, if available, by the audit committee. Short-term and long-term planning is the responsibility of audit management. The objectives and scope of each IS audit should be agreed to in an engagement letter. A training plan, based on the audit plan, should be developed by audit management.

QUESTION 779

An IS auditor is evaluating management's risk assessment of information systems. The IS auditor should FIRST review:

- A. the controls already in place.
- B. the effectiveness of the controls in place.
- C. the mechanism for monitoring the risks related to the assets.
- D. the threats/vulnerabilities affecting the assets.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

One of the key factors to be considered while assessing the risks related to the use of various information systems is the threats and vulnerabilities affecting the assets. The risks related to the use of information assets should be evaluated in isolation from the installed controls. Similarly, the effectiveness of the controls should be considered during the risk mitigation stage and not during the risk assessment phase. A mechanism to continuously monitor the risks related to assets should be put in place during the risk monitoring function that follows the risk assessment phase.

QUESTION 780

In planning an audit, the MOST critical step is the identification of the:

- A. areas of high risk.
- B. skill sets of the audit staff.
- C. test steps in the audit.
- D. time allotted for the audit.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When designing an audit plan, it is important to identify the areas of highest risk to determine the areas to be audited. The skill sets of the audit staff should have been considered before deciding and selecting the audit. Test steps for the audit are not as critical as identifying the areas of risk, and the time allotted for an audit is determined by the areas to be audited, which are primarily selected based on the identification of risks.

QUESTION 781

The extent to which data will be collected during an IS audit should be determined based on the:

- A. availability of critical and required information.
- B. auditor's familiarity with the circumstances.
- C. auditee's ability to find relevant evidence.
- D. purpose and scope of the audit being done.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The extent to which data will be collected during an IS audit should be related directly to the scope and purpose of the audit. An audit with a narrow purpose and scope would result most likely in less data collection, than an audit with a wider purpose and scope. The scope of an IS audit should not be constrained by the ease of obtaining the information or by the auditor's familiarity with the area being audited. Collecting all the required evidence is a required element of an IS audit, and the scope of the audit should not be limited by the auditee's ability to find relevant evidence.

QUESTION 782

While planning an audit, an assessment of risk should be made to provide:

- A. reasonable assurance that the audit will cover material items.
- B. definite assurance that material items will be covered during the audit work.
- C. reasonable assurance that all items will be covered by the audit.
- D. sufficient assurance that all items will be covered during the audit work.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The ISACA IS Auditing Guideline G15 on planning the IS audit states, 'An assessment of risk should be made to provide reasonable assurance that material items will be adequately covered during the audit work. This assessment should identify areas with a relatively high risk of the existence of material problems.' Definite assurance that material items will be covered during the audit work is an impractical proposition. Reasonable assurance that all items will be covered during the audit work is not the correct answer, as material items need to be covered, not all items.

QUESTION 783

An IS auditor should use statistical sampling and not judgment (nonstatistical) sampling, when:

- A. the probability of error must be objectively quantified.
- B. the auditor wishes to avoid sampling risk.
- C. generalized audit software is unavailable.
- D. the tolerable error rate cannot be determined.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Given an expected error rate and confidence level, statistical sampling is an objective method of sampling, which helps an IS auditor determine the sample size and quantify the probability of error (confidence coefficient). Choice B is incorrect because sampling risk is the risk of a sample not being representative of the population. This risk exists for both judgment and statistical samples. Choice C is incorrect because statistical sampling does not require the use of generalized audit software. Choice D is incorrect because the tolerable error rate must be predetermined for both judgment and statistical sampling.

QUESTION 784

During the planning stage of an IS audit, the PRIMARY goal of an IS auditor is to:

- A. address audit objectives.
- B. collect sufficient evidence.
- C. specify appropriate tests.
- D. minimize audit resources.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

ISACA auditing standards require that an IS auditor plan the audit work to address the audit objectives. Choice B is incorrect because the auditor does not collect evidence in the planning stage of an audit. Choices C and D are incorrect because they are not the primary goals of audit planning. The activities described in choices B, C and D are all undertaken to address audit objectives and are thus secondary to choice A.

QUESTION 785

When selecting audit procedures, an IS auditor should use professional judgment to ensure that:

- A. sufficient evidence will be collected.
- B. all significant deficiencies identified will be corrected within a reasonable period.
- C. all material weaknesses will be identified.
- D. audit costs will be kept at a minimum level.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Procedures are processes an IS auditor may follow in an audit engagement. In determining the appropriateness of any specific procedure, an IS auditor should use professional judgment appropriate to the specific circumstances. Professional judgment involves a subjective and often qualitative evaluation of conditions arising in the course of an audit. Judgment addresses a grey area where binary (yes/no) decisions are not appropriate and the auditor's past experience plays a key role in making a judgment. ISACA's guidelines provide information on how to meet the standards when performing IS audit work. Identifying material weaknesses is the result of appropriate competence, experience and thoroughness in planning and executing the audit and not of professional judgment. Professional judgment is not a primary input to the financial aspects of the audit.

QUESTION 786

An IS auditor evaluating logical access controls should FIRST:

- A. document the controls applied to the potential access paths to the system.
- B. test controls over the access paths to determine if they are functional.
- C. evaluate the security environment in relation to written policies and practices
- D. obtain an understanding of the security risks to information processing.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When evaluating logical access controls, an IS auditor should first obtain an understanding of the security risks facing information processing by reviewing relevant documentation, by inquiries, and by conducting a risk assessment. Documentation and evaluation is the second step in assessing the adequacy, efficiency and effectiveness, thus identifying deficiencies or redundancy in controls. The third step is to test the access paths- to determine if the controls are functioning. Lastly, the IS auditor evaluates the security environment to assess its adequacy by reviewing the written policies, observing practices and comparing them to appropriate security best practices.

QUESTION 787

The PRIMARY purpose of an IT forensic audit is:

- A. to participate in investigations related to corporate fraud.
- B. the systematic collection of evidence after a system irregularity.
- C. to assess the correctness of an organization's financial statements
- D. to determine that there has been criminal activity.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Choice B describes a forensic audit. The evidence collected could then be used in judicial proceedings. Forensic audits are not limited to corporate fraud.

Assessing the correctness of an organization's financial statements is not the purpose of a forensic audit. Drawing a conclusion to criminal activity would be part of a legal process and not the objective of a forensic audit.

QUESTION 788

An IS auditor is performing an audit of a remotely managed server backup. The IS auditor reviews the logs for one day and finds one case where logging on a server has failed with the result that backup restarts cannot be confirmed. What should the auditor do?

- A. Issue an audit finding
- B. Seek an explanation from IS management
- C. Review the classifications of data held on the server
- D. Expand the sample of logs reviewed

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Audit standards require that an IS auditor gather sufficient and appropriate audit evidence. The auditor has found a potential problem and now needs to determine if this is an isolated incident or a systematic control failure. At this stage it is too preliminary to issue an audit finding and seeking an explanation from management is advisable, but it would be better to gather additional evidence to properly evaluate the seriousness of the situation. A backup failure, which has not been established at this point, will be serious if it involves critical data. However, the issue is not the importance of the data on the server, where a problem has been detected, but whether a systematic control failure that impacts other servers exists.

QUESTION 789

In an IS audit of several critical servers, the IS auditor wants to analyze audit trails to discover potential anomalies in user or system behavior. Which of the following tools are MOST suitable for performing that task?

- A. CASE tools
- B. Embedded data collection tools
- C. Heuristic scanning tools
- D. Trend/variance detection tools

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Trend/variance detection tools look for anomalies in user or system behavior, for example, determining whether the numbers for prenumbered documents are sequential or increasing. CASE tools are used to assist software development. Embedded (audit) data collection software is used for sampling and to provide production statistics. Heuristic scanning tools can be used to scan for viruses to indicate possible infected code.

QUESTION 790

An IS auditor is evaluating a corporate network for a possible penetration by employees. Which of the following findings should give the IS auditor the GREATEST concern?

- A. There are a number of external modems connected to the network.
- B. Users can install software on their desktops.
- C. Network monitoring is very limited.
- D. Many user IDs have identical passwords.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Exploitation of a known user ID and password requires minimal technical knowledge and exposes the network resources to exploitation. The technical barrier is low and the impact can be very high; therefore, the fact that many user IDs have identical passwords represents the greatest threat. External modems represent a security risk, but exploitation still depends on the use of a valid user account. While the impact of users installing software on their desktops can be high (for example, due to the installation of Trojans or key-logging programs), the likelihood is not high due to the level of technical knowledge required to successfully penetrate the network. Although network monitoring can be a useful detective control, it will only detect abuse of user accounts in special circumstances and is, therefore, not a first line of defense.

QUESTION 791

Which of the following is the PRIMARY advantage of using computer forensic software for investigations?

- A. The preservation of the chain of custody for electronic evidence
- B. Time and cost savings
- C. Efficiency and effectiveness
- D. Ability to search for violations of intellectual property rights

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary objective of forensic software is to preserve electronic evidence to meet the rules of evidence. Choice B, time and cost savings, and choice C, efficiency and effectiveness, are legitimate concerns that differentiate good from poor forensic software packages. Choice D, the ability to search for intellectual property rights violations, is an example of a use of forensic software.

QUESTION 792

An IS auditor has imported data from the client's database. The next step-confirming whether the imported data are complete-is performed by:

- A. matching control totals of the imported data to control totals of the original data.
- B. sorting the data to confirm whether the data are in the same order as the original data.
- C. reviewing the printout of the first 100 records of original data with the first 100 records of imported data.
- D. filtering data for different categories and matching them to the original data.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Matching control totals of the imported data with control totals of the original data is the next logical step, as this confirms the completeness of the imported data. It is not possible to confirm completeness by sorting the imported data, because the original data may not be in sorted order. Further, sorting does not provide control totals for verifying completeness. Reviewing a printout of 100 records of original data with 100 records of

imported data is a process of physical verification and confirms the accuracy of only these records. Filtering data for different categories and matching them to original data would still require that control totals be developed to confirm the completeness of the data.

QUESTION 793

The vice president of human resources has requested an audit to identify payroll overpayments for the previous year. Which would be the BEST audit technique to use in this situation?

- A. Test data
- B. Generalized audit software
- C. Integrated test facility
- D. Embedded audit module

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Generalized audit software features include mathematical computations, stratification, statistical analysis, sequence checking, duplicate checking and recomputations. An IS auditor, using generalized audit software, could design appropriate tests to recompute the payroll, thereby determining if there were overpayments and to whom they were made. Test data would test for the existence of controls that might prevent overpayments, but it would not detect specific, previous miscalculations. Neither an integrated test facility nor an embedded audit module would detect errors for a previous period.

QUESTION 794

During a security audit of IT processes, an IS auditor found that there were no documented security procedures. The IS auditor should:

- A. create the procedures document.

- B. terminate the audit.
- C. conduct compliance testing.
- D. identify and evaluate existing practices.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

One of the main objectives of an audit is to identify potential risks; therefore, the most proactive approach would be to identify and evaluate the existing security practices being followed by the organization. IS auditors should not prepare documentation, as doing so could jeopardize their independence. Terminating the audit may prevent achieving one of the basic audit objectives, i.e., identification of potential risks. Since there are no documented procedures, there is no basis against which to test compliance.

QUESTION 795

In the course of performing a risk analysis, an IS auditor has identified threats and potential impacts. Next, the IS auditor should:

- A. identify and assess the risk assessment process used by management.
- B. identify information assets and the underlying systems.
- C. disclose the threats and impacts to management.
- D. identify and evaluate the existing controls.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is important for an IS auditor to identify and evaluate the existing controls and security once the potential threats and possible impacts are identified. Upon completion of an audit an IS auditor should describe and discuss with management the threats and potential impacts on the assets.

QUESTION 796

Which of the following should be of MOST concern to an IS auditor?

- A. Lack of reporting of a successful attack on the network
- B. Failure to notify police of an attempted intrusion
- C. Lack of periodic examination of access rights
- D. Lack of notification to the public of an intrusion

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Not reporting an intrusion is equivalent to an IS auditor hiding a malicious intrusion, which would be a professional mistake. Although notification to the police may be required and the lack of a periodic examination of access rights might be a concern, they do not represent as big a concern as the failure to report the attack. Reporting to the public is not a requirement and is dependent on the organization's desire, or lack thereof, to make the intrusion known.

QUESTION 797

Which of the following would normally be the MOST reliable evidence for an auditor?

- A. A confirmation letter received from a third party verifying an account balance
- B. Assurance from line management that an application is working as designed
- C. Trend data obtained from World Wide Web (Internet) sources
- D. Ratio analysts developed by the IS auditor from reports supplied by line management

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Evidence obtained from independent third parties almost always is considered to be the most reliable. Choices B, C and D would not be considered as reliable.

QUESTION 798

When evaluating the collective effect of preventive, detective or corrective controls within a process, an IS auditor should be aware of which of the following?

- A. The point at which controls are exercised as data flow through the system
- B. Only preventive and detective controls are relevant
- C. Corrective controls can only be regarded as compensating
- D. Classification allows an IS auditor to determine which controls are missing

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor should focus on when controls are exercised as data flow through a computer system. Choice B is incorrect since corrective controls may also be relevant. Choice C is incorrect, since corrective controls remove or reduce the effects of errors or irregularities and are exclusively regarded as compensating controls. Choice D is incorrect and irrelevant since the existence and function of controls is important, not the classification.

QUESTION 799

Which audit technique provides the BEST evidence of the segregation of duties in an IS department?

- A. Discussion with management
- B. Review of the organization chart
- C. Observation and interviews
- D. Testing of user access rights

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

By observing the IS staff performing their tasks, an IS auditor can identify whether they are performing any incompatible operations, and by interviewing the IS staff, the auditor can get an overview of the tasks performed. Based on the observations and interviews the auditor can evaluate the segregation of duties. Management may not be aware of the detailed functions of each employee in the IS department; therefore, discussion with the management would provide only limited information regarding segregation of duties. An organization chart would not provide details of the functions of the employees. Testing of user rights would provide information about the rights they have within the IS systems, but would not provide complete information about the functions they perform.

QUESTION 800

During a review of a customer master file, an IS auditor discovered numerous customer name duplications arising from variations in customer first names. To determine the extent of the duplication, the IS auditor would use:

- A. test data to validate data input.
- B. test data to determine system sort capabilities.
- C. generalized audit software to search for address field duplications.
- D. generalized audit software to search for account field duplications.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Since the name is not the same {due to name variations}, one method to detect duplications would be to compare other common fields, such as addresses. A subsequent review to determine common customer names at these addresses could then be conducted. Searching for duplicate account numbers would not likely find duplications, since customers would most likely have different account numbers for each variation. Test data would not be useful to detect the extent of any data characteristic, but simply to determine how the data were processed.

QUESTION 801

Which of the following would be the BEST population to take a sample from when testing program changes?

- A. Test library listings
- B. Source program listings
- C. Program change requests
- D. Production library listings

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The best source from which to draw any sample or test of system information is the automated system. The production libraries represent executables that are approved and authorized to process organizational data. Source program listings would be timeintensive. Program change requests are the documents used to initiate change; there is no guarantee that the request has been completed for all changes. Test library listings do not represent the approved and authorized executables.

QUESTION 802

An integrated test facility is considered a useful audit tool because it:

- A. is a cost-efficient approach to auditing application controls.
- B. enables the financial and IS auditors to integrate their audit tests.
- C. compares processing output with independently calculated data.
- D. provides the IS auditor with a tool to analyze a large range of information

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An integrated test facility is considered a useful audit tool because it uses the same programs to compare processing using independently calculated data. This involves setting up dummy entities on an application system and processing test or production data against the entity as a means of verifying processing accuracy.

QUESTION 803

Data flow diagrams are used by IS auditors to:

- A. order data hierarchically.
- B. highlight high-level data definitions.
- C. graphically summarize data paths and storage.
- D. portray step-by-step details of data generation.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data flow diagrams are used as aids to graph or chart data flow and storage. They trace the data from its origination to destination, highlighting the paths and storage of data. They do not order data in any hierarchy. The flow of the data will not necessarily match any hierarchy or data generation order.

QUESTION 804

Which of the following forms of evidence for the auditor would be considered the MOST reliable?

- A. An oral statement from the auditee
- B. The results of a test performed by an IS auditor
- C. An internally generated computer accounting report
- D. A confirmation letter received from an outside source

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Evidence obtained from outside sources is usually more reliable than that obtained from within the organization. Confirmation letters received from outside parties, such as those used to verify accounts receivable balances, are usually highly reliable. Testing performed by an auditor may not be reliable, if the auditor did not have a good understanding of the technical area under review.

QUESTION 805

An IS auditor reviews an organizational chart PRIMARILY for:

- A. an understanding of workflows.
- B. investigating various communication channels.
- C. understanding the responsibilities and authority of individuals.
- D. investigating the network connected to different employees.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

An organizational chart provides information about the responsibilities and authority of individuals in the organization. This helps an IS auditor to know if there is a proper segregation of functions. A workflow chart would provide information about the roles of different employees. A network diagram will provide information about the usage of various communication channels and will indicate the connection of users to the network.

QUESTION 806

An IS auditor is performing an audit of a network operating system. Which of the following is a user feature the IS auditor should review?

- A. Availability of online network documentation
- B. Support of terminal access to remote hosts
- C. Handling file transfer between hosts and interuser communications
- D. Performance management, audit and control

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Network operating system user features include online availability of network documentation. Other features would be user access to various resources of network hosts, user authorization to access particular resources,

and the network and host computers used without special user actions or commands. Choices B, C and D are examples of network operating systems functions.

QUESTION 807

An IS auditor attempting to determine whether access to program documentation is restricted to authorized persons would MOST likely:

- A. evaluate the record retention plans for off-premises storage.
- B. interview programmers about the procedures currently being followed.
- C. compare utilization records to operations schedules.
- D. review data file access records to test the librarian function.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Asking programmers about the procedures currently being followed is useful in determining whether access to program documentation is restricted to authorized persons. Evaluating the record retention plans for off-premises storage tests the recovery procedures, not the access control over program documentation. Testing utilization records or data files will not address access security over program documentation.

QUESTION 808

Which of the following is an advantage of an integrated test facility (ITF)?

- A. It uses actual master files or dummies and the IS auditor does not have to review the source of the transaction.
- B. Periodic testing does not require separate test processes.
- C. It validates application systems and tests the ongoing operation of the system.
- D. The need to prepare test data is eliminated.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

An integrated test facility creates a fictitious entity in the database to process test transactions simultaneously with live input. Its advantage is that periodic testing does not require separate test processes. However, careful planning is necessary, and test data must be isolated from production data.

QUESTION 809

An IS auditor evaluates the test results of a modification to a system that deals with payment computation. The auditor finds that 50 percent of the calculations do not match predetermined totals. Which of the following would MOST likely be the next step in the audit?

- A. Design further tests of the calculations that are in error.
- B. Identify variables that may have caused the test results to be inaccurate.
- C. Examine some of the test cases to confirm the results.
- D. Document the results and prepare a report of findings, conclusions and recommendations.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

An IS auditor should next examine cases where incorrect calculations occurred and confirm the results. After the calculations have been confirmed, further tests can be conducted and reviewed. Report preparation, findings and recommendations would not be made until all results are confirmed.

QUESTION 810

The BEST method of proving the accuracy of a system tax calculation is by:

- A. detailed visual review and analysis of the source code of the calculation programs
- B. recreating program logic using generalized audit software to calculate monthly totals.
- C. preparing simulated transactions for processing and comparing the results to predetermined results.
- D. automatic flowcharting and analysis of the source code of the calculation programs.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Preparing simulated transactions for processing and comparing the results to predetermined results is the best method for proving accuracy of a tax calculation. Detailed visual review, flowcharting and analysis of source code are not effective methods, and monthly totals would not address the accuracy of individual tax calculations.

QUESTION 811

An IS auditor performing a review of an application's controls would evaluate the:

- A. efficiency of the application in meeting the business processes.
- B. impact of any exposures discovered.
- C. business processes served by the application.
- D. application's optimization.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An application control review involves the evaluation of the application's automated controls and an assessment of any exposures resulting from the control weaknesses. The other choices may be objectives of an application audit but are not part of an audit restricted to a review of controls.

QUESTION 812

In an audit of an inventory application, which approach would provide the BEST evidence that purchase orders are valid?

- A. Testing whether inappropriate personnel can change application parameters
- B. Tracing purchase orders to a computer listing
- C. Comparing receiving reports to purchase order details
- D. Reviewing the application documentation

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

To determine purchase order validity, testing access controls will provide the best evidence. Choices B and C are based on after-the-fact approaches, while choice D does not serve the purpose because what is in the system documentation may not be the same as what is happening.

QUESTION 813

Which of the following online auditing techniques is most effective for the early detection of errors or irregularities?

- A. Embedded audit module
- B. Integrated test facility
- C. Snapshots
- D. Audit hooks

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The audit hook technique involves embedding code in application systems for the examination of selected transactions. This helps an IS auditor to act before an error or an irregularity gets out of hand. An embedded audit module involves embedding specially-written software in the organization's host application system so that application systems are monitored on a selective basis. An integrated test facility is used when it is not practical to use test data, and snapshots are used when an audit trail is required.

QUESTION 814

When assessing the design of network monitoring controls, an IS auditor should FIRST review network:

- A. topology diagrams.
- B. bandwidth usage.
- C. traffic analysis reports.
- D. bottleneck locations.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The first step in assessing network monitoring controls should be the review of the adequacy of network documentation, specifically topology diagrams. If this information is not up to date, then monitoring processes and the ability to diagnose problems will not be effective.

QUESTION 815

While conducting an audit, an IS auditor detects the presence of a virus. What should be the IS auditor's next step?

- A. Observe the response mechanism.
- B. Clear the virus from the network.
- C. Inform appropriate personnel immediately.
- D. Ensure deletion of the virus.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The first thing an IS auditor should do after detecting the virus is to alert the organization to its presence, then wait for their response. Choice A should be taken after choice C. This will enable an IS auditor to examine the actual workability and effectiveness of the response system. An IS auditor should not make changes to the system being audited, and ensuring the deletion of the virus is a management responsibility.

QUESTION 816

A substantive test to verify that tape library inventory records are accurate is:

- A. determining whether bar code readers are installed.
- B. determining whether the movement of tapes is authorized.
- C. conducting a physical count of the tape inventory.
- D. checking if receipts and issues of tapes are accurately recorded.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A substantive test includes gathering evidence to evaluate the integrity of individual transactions, data or other information. Conducting a physical count of the tape inventory is a substantive test. Choices A, B and D are compliance tests.

QUESTION 817

When performing a computer forensic investigation, in regard to the evidence gathered, an IS auditor should be MOST concerned with:

- A. analysis.
- B. evaluation.
- C. preservation.
- D. disclosure.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Preservation and documentation of evidence for review by law enforcement and judicial authorities are of primary concern when conducting an investigation. Failure to properly preserve the evidence could jeopardize the acceptance of the evidence in legal proceedings. Analysis, evaluation and disclosure are important but not of primary concern in a forensic investigation.

QUESTION 818

An IS auditor interviewing a payroll clerk finds that the answers do not support job descriptions and documented procedures. Under these circumstances, the IS auditor should:

- A. conclude that the controls are inadequate.
- B. expand the scope to include substantive testing
- C. place greater reliance on previous audits.
- D. suspend the audit.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

If the answers provided to an IS auditor's questions are not confirmed by documented procedures or job descriptions, the IS auditor should expand the scope of testing the controls and include additional substantive tests. There is no evidence that whatever controls might exist are either inadequate or adequate. Placing greater reliance on previous audits or suspending the audit are inappropriate actions as they provide no current knowledge of the adequacy of the existing controls.

QUESTION 819

An IS auditor issues an audit report pointing out the lack of firewall protection features at the perimeter network gateway and recommends a vendor product to address this vulnerability. The IS auditor has failed to exercise:

- A. professional independence
- B. organizational independence.
- C. technical competence.
- D. professional competence.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When an IS auditor recommends a specific vendor, they compromise professional independence. Organizational independence has no relevance to the content of an audit report and should be considered at the time of accepting the engagement. Technical and professional competence is not relevant to the requirement of independence.

QUESTION 820

The PRIMARY reason an IS auditor performs a functional walkthrough during the preliminary phase of an audit assignment is to:

- A. understand the business process.

- B. comply with auditing standards.
- C. identify control weakness.
- D. plan substantive testing.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Understanding the business process is the first step an IS auditor needs to perform. Standards do not require an IS auditor to perform a process walkthrough. Identifying control weaknesses is not the primary reason for the walkthrough and typically occurs at a later stage in the audit, while planning for substantive testing is performed at a later stage in the audit.

QUESTION 821

In the process of evaluating program change controls, an IS auditor would use source code comparison software to:

- A. examine source program changes without information from IS personnel.
- B. detect a source program change made between acquiring a copy of the source and the comparison run.
- C. confirm that the control copy is the current version of the production program.
- D. ensure that all changes made in the current source copy are detected.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor has an objective, independent and relatively complete assurance of program changes because the source code comparison will identify changes.

Choice B is incorrect, because the changes made since the acquisition of the copy are not included in the copy of the software. Choice C is incorrect, as an IS auditor will have to gain this assurance separately.

Choice D is incorrect, because any changes made between the time the control copy was acquired and the source code comparison is made will not be detected.

QUESTION 822

The PRIMARY purpose for meeting with auditees prior to formally closing a review is to:

- A. confirm that the auditors did not overlook any important issues.
- B. gain agreement on the findings.
- C. receive feedback on the adequacy of the audit procedures.
- D. test the structure of the final presentation.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary purpose for meeting with auditees prior to formally closing a review is to gain agreement on the findings. The other choices, though related to the formal closure of an audit, are of secondary importance.

QUESTION 823

Which of the following audit techniques would BEST aid an auditor in determining whether there have been unauthorized program changes since the last authorized program update?

- A. Test data run
- B. Code review
- C. Automated code comparison
- D. Review of code migration procedures

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An automated code comparison is the process of comparing two versions of the same program to determine whether the two correspond. It is an efficient technique because it is an automated procedure. Test data runs permit the auditor to verify the processing of preselected transactions, but provide no evidence about unexercised portions of a program. Code review is the process of reading program source code listings to determine whether the code contains potential errors or inefficient statements. A code review can be used as a

means of code comparison but it is inefficient. The review of code migration procedures would not detect program changes.

QUESTION 824

Though management has stated otherwise, an IS auditor has reasons to believe that the organization is using software that is not licensed. In this situation, the IS auditor should:

- A. include the statement of management in the audit report.
- B. identify whether such software is, indeed, being used by the organization.
- C. reconfirm with management the usage of the software.
- D. discuss the issue with senior management since reporting this could have a negative impact on the organization.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When there is an indication that an organization might be using unlicensed software, the IS auditor should obtain sufficient evidence before including it in the report. With respect to this matter, representations obtained from management cannot be independently verified. If the organization is using software that is not licensed, the auditor, to maintain objectivity and independence, must include this in the report.

QUESTION 825

While reviewing sensitive electronic work papers, the IS auditor noticed that they were not encrypted. This could compromise the:

- A. audit trail of the versioning of the work papers.
- B. approval of the audit phases.
- C. access rights to the work papers.
- D. confidentiality of the work papers.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Encryption provides confidentiality for the electronic work papers. Audit trails, audit phase approvals and access to the work papers do not, of themselves, affect the confidentiality but are part of the reason for requiring encryption.

QUESTION 826

The MOST important reason for an IS auditor to obtain sufficient and appropriate audit evidence is to:

- A. comply with regulatory requirements.
- B. provide a basis for drawing reasonable conclusions.
- C. ensure complete audit coverage.
- D. perform the audit according to the defined scope.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The scope of an IS audit is defined by its objectives. This involves identifying control weaknesses relevant to the scope of the audit. Obtaining sufficient and appropriate evidence assists the auditor in not only identifying control weaknesses but also documenting and validating them.

Complying with regulatory requirements, ensuring coverage and the execution of audit are all relevant to an audit but are not the reason why sufficient and relevant evidence is required.

QUESTION 827

After initial investigation, an IS auditor has reasons to believe that fraud may be present.

The IS auditor should:

- A. expand activities to determine whether an investigation is warranted
- B. report the matter to the audit committee.
- C. report the possibility of fraud to top management and ask how they would like to be proceed.
- D. consult with external legal counsel to determine the course of action to be taken.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor's responsibilities for detecting fraud include evaluating fraud indicators and deciding whether any additional action is necessary or whether an investigation should be recommended. The IS auditor should notify the appropriate authorities within the organization only if it has determined that the indicators of fraud are sufficient to recommend an investigation. Normally, the IS auditor does not have authority to consult with external legal counsel.

QUESTION 828

Which of the following should an IS auditor use to detect duplicate invoice records within an invoice master file?

- A. Attribute sampling
- B. Generalized audit software (GAS)
- C. Test data
- D. Integrated test facility (ITF)

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Generalized audit software (GAS) would enable the auditor to review the entire invoice file to look for those items that meet the selection criteria. Attribute sampling would aid in identifying records meeting specific conditions, but would not compare one record to another to identify duplicates. To detect duplicate invoice records, the IS auditor should check all of the items that meet the criteria and not just a sample of the items. Test data are used to verify program processing, but will not identify duplicate records. An integrated test facility (ITF) allows the IS auditor to test transactions through the production system, but would not compare records to identify duplicates.

QUESTION 829

Which of the following would be the MOST effective audit technique for identifying segregation of duties violations in a new enterprise resource planning (ERP) implementation?

- A. Reviewing a report of security rights in the system
- B. Reviewing the complexities of authorization objects
- C. Building a program to identify conflicts in authorization
- D. Examining recent access rights violation cases

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Since the objective is to identify violations in segregation of duties, it is necessary to define the logic that will identify conflicts in authorization. A program could be developed to identify these conflicts. A report of security rights in the enterprise resource planning (ERP) system would be voluminous and time consuming to review; therefore, this technique is not as effective as building a program. As complexities increase, it becomes more difficult to verify the effectiveness of the systems and complexity is not, in itself, a link to segregation of duties. It is good practice to review recent access rights violation cases; however, it may require a significant amount of time to truly identify which violations actually resulted from an inappropriate segregation of duties.

QUESTION 830

Which of the following would an IS auditor use to determine if unauthorized modifications were made to production programs?

- A. System log analysis
- B. Compliance testing
- C. Forensic analysis
- D. Analytical review

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Determining that only authorized modifications are made to production programs would require the change management process be reviewed to evaluate the existence of a trail of documentary evidence. Compliance testing would help to verify that the change management process has been applied consistently. It is unlikely that the system log analysis would provide information about the modification of programs. Forensic analysis is a specialized technique for criminal investigation. An analytical review assesses the general control environment of an organization.

QUESTION 831

During a change control audit of a production system, an IS auditor finds that the change management process is not formally documented and that some migration procedures failed. What should the IS auditor do next?

- A. Recommend redesigning the change management process.
- B. Gain more assurance on the findings through root cause analysis.
- C. Recommend that program migration be stopped until the change process is documented.
- D. Document the finding and present it to management.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A change management process is critical to IT production systems. Before recommending that the

organization take any other action (e.g., stopping migrations, redesigning the change management process), the IS auditor should gain assurance that the incidents reported are related to deficiencies in the change management process and not caused by some process other than change management.

QUESTION 832

During the collection of forensic evidence, which of the following actions would MOST likely result in the destruction or corruption of evidence on a compromised system?

- A. Dumping the memory content to a file
- B. Generating disk images of the compromised system
- C. Rebooting the system
- D. Removing the system from the network

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Rebooting the system may result in a change in the system state and the loss of files and important evidence stored in memory. The other choices are appropriate actions for preserving evidence.

QUESTION 833

An IS auditor who was involved in designing an organization's business continuity plan (BCP) has been assigned to audit the plan. The IS auditor should:

- A. decline the assignment.
- B. inform management of the possible conflict of interest after completing the audit assignment.
- C. inform the business continuity planning (BCP) team of the possible conflict of interest prior to beginning the assignment.
- D. communicate the possibility of conflict of interest to management prior to starting the assignment.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Communicating the possibility of a conflict of interest to management prior to starting the assignment is the correct answer. A possible conflict of interest, likely to affect the auditor's independence, should be brought to the attention of management prior to starting the assignment. Declining the assignment is not the correct answer because the assignment could be accepted after obtaining management approval. Informing management of the possible conflict of interest after completion of the audit assignment is not correct because approval should be obtained prior to commencement and not after the completion of the assignment. Informing the business continuity planning (BCP) team of the possible conflict of interest prior to starting of the assignment is not the correct answer since the BCP team would not have the authority to decide on this issue.

QUESTION 834

An IS auditor conducting a review of software usage and licensing discovers that numerous PCs contain unauthorized software. Which of the following actions should the IS auditor take?

- A. Personally delete all copies of the unauthorized software.
- B. Inform the auditee of the unauthorized software, and follow up to confirm deletion.
- C. Report the use of the unauthorized software and the need to prevent recurrence to auditee management.
- D. Take no action, as it is a commonly accepted practice and operations management is responsible for monitoring such use.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The use of unauthorized or illegal software should be prohibited by an organization. Software piracy results in inherent exposure and can result in severe fines. An IS auditor must convince the user and user management of the risk and the need to eliminate the risk. An IS auditor should not assume the role of the enforcing

officer and take on any personal involvement in removing or deleting the unauthorized software.

QUESTION 835

Corrective action has been taken by an auditee immediately after the identification of a reportable finding. The auditor should:

- A. include the finding in the final report, because the IS auditor is responsible for an accurate report of all findings.
- B. not include the finding in the final report, because the audit report should include only unresolved findings.
- C. not include the finding in the final report, because corrective action can be verified by the IS auditor during the audit.
- D. include the finding in the closing meeting for discussion purposes only.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Including the finding in the final report is a generally accepted audit practice. If an action is taken after the audit started and before it ended, the audit report should identify the finding and describe the corrective action taken. An audit report should reflect the situation, as it existed at the start of the audit. All corrective actions taken by the auditee should be reported in writing.

QUESTION 836

During an implementation review of a multiuser distributed application, an IS auditor finds minor weaknesses in three areas-the initial setting of parameters is improperly installed, weak passwords are being used and some vital reports are not being checked properly. While preparing the audit report, the IS auditor should:

- A. record the observations separately with the impact of each of them marked against each respective finding.
- B. advise the manager of probable risks without recording the observations, as the control weaknesses are minor ones.
- C. record the observations and the risk arising from the collective weaknesses.
- D. apprise the departmental heads concerned with each observation and properly document it in the report.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Individually the weaknesses are minor; however, together they have the potential to substantially weaken the overall control structure. Choices A and D reflect a failure on the part of an IS auditor to recognize the combined effect of the control weakness. Advising the local manager without reporting the facts and observations would conceal the findings from other stakeholders.

QUESTION 837

During an exit interview, in cases where there is disagreement regarding the impact of a finding, an IS auditor should:

- A. ask the auditee to sign a release form accepting full legal responsibility.
- B. elaborate on the significance of the finding and the risks of not correcting it.
- C. report the disagreement to the audit committee for resolution.
- D. accept the auditee's position since they are the process owners.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If the auditee disagrees with the impact of a finding, it is important for an IS auditor to elaborate and clarify the risks and exposures, as the auditee may not fully appreciate the magnitude of the exposure. The goal should be to enlighten the auditee or uncover new information of which an IS auditor may not have been aware. Anything that appears to threaten the auditee will lessen effective communications and set up an adversarial relationship. By the same token, an IS auditor should not automatically agree just because the auditee expresses an alternate point of view.

QUESTION 838

When preparing an audit report, the IS auditor should ensure that the results are supported by:

- A. statements from IS management.
- B. workpapers of other auditors.
- C. an organizational control self-assessment.
- D. sufficient and appropriate audit evidence.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

ISACA's standard on 'reporting' requires the IS auditor have sufficient and appropriate audit evidence to support the reported results. Statements from IS management provide a basis for obtaining concurrence on matters that cannot be verified with empirical evidence. The report should be based on evidence collected during the course of the review even though the auditor may have access to the work papers of other auditors. The results of an organizational control self-assessment (CSA) could supplement the audit findings. Choices A, B and C might be referenced during an audit but, of themselves, would not be considered a sufficient basis for issuing a report.

QUESTION 839

The final decision to include a material finding in an audit report should be made by the:

- A. audit committee.
- B. auditee's manager.
- C. IS auditor.
- D. CEO of the organization

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The IS auditor should make the final decision about what to include or exclude from the audit report. The other choices would limit the independence of the auditor.

QUESTION 840

The success of control self-assessment (CSA) highly depends on:

- A. having line managers assume a portion of the responsibility for control monitoring.
- B. assigning staff managers the responsibility for building, but not monitoring, controls.
- C. the implementation of a stringent control policy and rule-driven controls.
- D. the implementation of supervision and the monitoring of controls of assigned duties.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary objective of a CSA program is to leverage the internal audit function by shifting some of the control monitoring responsibilities to the functional area line managers. The success of a control self-assessment (CSA) program depends on the degree to which line managers assume responsibility for controls- Choices B, C and D are characteristics of a traditional audit approach, not a CSA approach.

QUESTION 841

Which of the following is an attribute of the control self-assessment (CSA) approach?

- A. Broad stakeholder involvement
- B. Auditors are the primary control analysts
- C. Limited employee participation
- D. Policy driven

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The control self-assessment (CSA) approach emphasizes management of and accountability for developing and monitoring the controls of an organization's business processes. The attributes of CSA include empowered employees, continuous improvement, extensive employee participation and training, all of which are representations of broad stakeholder involvement. Choices B, C and D are attributes of a traditional audit approach.

QUESTION 842

Which of the following is the key benefit of control self-assessment (CSA)?

- A. Management ownership of the internal controls supporting business objectives is reinforced.
- B. Audit expenses are reduced when the assessment results are an input to external audit work.
- C. Improved fraud detection since internal business staff are engaged in testing controls
- D. Internal auditors can shift to a consultative approach by using the results of the assessment.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The objective of control self-assessment is to have business management become more aware of the importance of internal control and their responsibility in terms of corporate governance. Reducing audit expenses is not a key benefit of control self-assessment (CSA). Improved fraud detection is important, but not as important as ownership, and is not a principal objective of CSA. CSA may give more insights to internal auditors, allowing them to take a more consultative role; however, this is an additional benefit, not the key benefit.

QUESTION 843

An IT steering committee should review information systems PRIMARILY to assess:

- A. whether IT processes support business requirements.
- B. if proposed system functionality is adequate
- C. the stability of existing software.
- D. the complexity of installed technology.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The role of an IT steering committee is to ensure that the IS department is in harmony with the organization's mission and objectives. To ensure this, the committee must determine whether IS processes support the business requirements. Assessing proposed additional functionality and evaluating software stability and the complexity of technology are too narrow in scope to ensure that IT processes are, in fact, supporting the organization's goals.

QUESTION 844

The MOST likely effect of the lack of senior management commitment to IT strategic planning is:

- A. a lack of investment in technology.
- B. a lack of a methodology for systems development.
- C. technology not aligning with the organization's objectives.
- D. an absence of control over technology contracts.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A steering committee should exist to ensure that the IT strategies support the organization's goals. The absence of an information technology committee or a committee not composed of senior managers would be an indication of a lack of top-level management commitment. This condition would increase the risk that IT would not be aligned with the organization's strategy.

QUESTION 845

Which of the following is a function of an IS steering committee?

- A. Monitoring vendor-controlled change control and testing
- B. Ensuring a separation of duties within the information's processing environment
- C. Approving and monitoring major projects, the status of IS plans and budgets
- D. Liaising between the IS department and the end users

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The IS steering committee typically serves as a general review board for major IS projects and should not become involved in routine operations; therefore, one of its functions is to approve and monitor major projects, the status of IS plans and budgets. Vendor change control is an outsourcing issue and should be monitored by IS management. Ensuring a separation of duties within the information's processing environment is an IS management responsibility. Liaising between the IS department and the end users is a function of the individual parties and not a committee.

QUESTION 846

An IS steering committee should:

- A. include a mix of members from different departments and staff levels.
- B. ensure that IS security policies and procedures have been executed properly.
- C. have formal terms of reference and maintain minutes of its meetings.
- D. be briefed about new trends and products at each meeting by a vendor.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is important to keep detailed steering committee minutes to document the decisions and activities of the IS steering committee, and the board of directors should be informed about those decisions on a timely basis. Choice A is incorrect because only senior management or high-level staff members should be on this committee because of its strategic mission. Choice B is not a responsibility of this committee, but the responsibility of the security administrator. Choice D is incorrect because a vendor should be invited to meetings only when appropriate.

QUESTION 847

Involvement of senior management is MOST important in the development of:

- A. strategic plans.
- B. IS policies.
- C. IS procedures.
- D. standards and guidelines.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Strategic plans provide the basis for ensuring that the enterprise meets its goals and objectives. Involvement of senior management is critical to ensuring that the plan adequately addresses the established goals and objectives. IS policies, procedures, standards and guidelines are all structured to support the overall strategic plan.

QUESTION 848

Effective IT governance will ensure that the IT plan is consistent with the organization's:

- A. business plan.
- B. audit plan.
- C. security plan.
- D. investment plan.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

To govern IT effectively, IT and business should be moving in the same direction, requiring that the IT plans are aligned with an organization's business plans. The audit and investment plans are not part of the IT plan, while the security plan should be at a corporate level.

QUESTION 849

Establishing the level of acceptable risk is the responsibility of:

- A. quality assurance management.
- B. senior business management.
- C. the chief information officer.
- D. the chief security officer.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Senior management should establish the acceptable risk level, since they have the ultimate or final responsibility for the effective and efficient operation of the organization. Choices A, C and D should act as advisors to senior management in determining an acceptable risk level.

QUESTION 850

IT governance is PRIMARILY the responsibility of the:

- A. chief executive officer.
- B. board of directors.

- C. IT steering committee.
- D. audit committee.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

IT governance is primarily the responsibility of the executives and shareholders (as represented by the board of directors). The chief executive officer is instrumental in implementing IT governance per the directions of the board of directors. The IT steering committee monitors and facilitates deployment of IT resources for specific projects in support of business plans. The audit committee reports to the board of directors and should monitor the implementation of audit recommendations.

QUESTION 851

As an outcome of information security governance, strategic alignment provides:

- A. security requirements driven by enterprise requirements.
- B. baseline security following best practices.
- C. institutionalized and commoditized solutions.
- D. an understanding of risk exposure.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Information security governance, when properly implemented, should provide four basic outcomes: strategic alignment, value delivery, risk management and performance measurement. Strategic alignment provides input for security requirements driven by enterprise requirements. Value delivery provides a standard set of security practices, i.e., baseline security following best practices or institutionalized and commoditized solutions. Risk management provides an understanding of risk exposure.

QUESTION 852

Which of the following IT governance best practices improves strategic alignment?

- A. Supplier and partner risks are managed.
- B. A knowledge base on customers, products, markets and processes is in place.
- C. A structure is provided that facilitates the creation and sharing of business information.
- D. Top management mediate between the imperatives of business and technology.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Top management mediating between the imperatives of business and technology is an IT strategic alignment best practice. Supplier and partner risks being managed is a risk management best practice. A knowledge base on customers, products, markets and processes being in place is an IT value delivery best practice. An infrastructure being provided to facilitate the creation and sharing of business information is an IT value delivery and risk management.

QUESTION 853

Which of the following is BEST addressed when using a timestamp within a digital signature to deliver sensitive financial information?

- A. Replay protection
- B. Authentication
- C. Nonrepudiation
- D. Data integrity

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 854

An organization has software that is not compliant with data protection requirements. To help ensure that appropriate and relevant data protection controls are implemented in the future, the auditor's BEST course of action would be to:

- A. conduct a privacy impact assessment to identify gaps in the organization's privacy.
- B. recommend that privacy checks are included within the solution development life cycle.
- C. recommend an executive be appointed to oversee privacy program improvements.
- D. map the organization's business processes to identify personally identifiable information (PII).

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 855

Which of the following would be of MOST concern during an audit of an end user computing system containing sensitive information?

- A. Audit logging is not available.
- B. System data is not protected.
- C. Secure authorization is not available.
- D. The system is not included in inventory.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 856

Following a recent internal data breach, an IS auditor was asked to evaluate information security practices within the organization. Which of the following findings would be MOST important to report to senior management?

- A. Employees are not required to sign a non-compete agreement.
- B. Security education and awareness workshops have not been completed.
- C. Users lack technical knowledge related to security and data protection.
- D. Desktop passwords do not require special characters.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 857

Which of the following is the BEST way to protect the confidentiality of data on a corporate smartphone?

- A. Disabling public wireless connections
- B. Using remote data wipe capabilities
- C. Using encryption
- D. Changing the default PIN for Bluetooth connections

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 858

To help ensure the organization's information assets are adequately protected, which of the following considerations is MOST important when developing an information classification and handling policy?

- A. The policy has been mapped against industry frameworks for classifying information assets.
- B. The policy is owned by the head of information security, who has the authority to enforce the policy.
- C. The policy specifies requirements to safeguard information assets based on their importance to the organization.
- D. The policy is subject to periodic reviews to ensure its provisions are up to date.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 859

An IS auditor has been asked to perform a post-implementation assessment of a new corporate human resources (HR) system. Which of the following control areas would be MOST important to review for the protection of employee information?

- A. Logging capabilities
- B. Authentication mechanisms
- C. Data retention practices
- D. System architecture

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 860

A multinational company wants to establish a mandatory global standard for information security including data protection and privacy. Which of the following should be the GREATEST concern to an IS auditor?

- A. Inconsistent roll-out of the standard across all countries.
- B. Increased organizational effort without any tangible benefit
- C. Noncompliance with local laws in the affected countries
- D. Lack of adoption by organized labor groups in all affected countries

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 861

An organization's current end-user computing practices include the use of a spreadsheet for financial statements. Which of the following is the GREATEST concern?

- A. Formulas are not protected against unintended changes.
- B. The spreadsheet contains numerous macros.
- C. Operational procedures have not been reviewed in the current fiscal year.
- D. The spreadsheet is not maintained by IT.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 862

A government organization uses standard Wi-Fi Protected Access 2 (WPA2) to protect confidential information transmitted to a file server. Which of the following is the IS auditor's BEST recommendation to further strengthen security?

- A. Certificate-based authentication
- B. Network address translation (NAT)
- C. Media access control (MAC) address filtering
- D. Service set identifier (SSID) masking

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 863

An IS auditor is assessing an organization's data loss prevention (DLP) solution for protecting intellectual property from insider theft. Which of the following would the auditor consider MOST important for effective data protection?

- A. Employee training on information handling
- B. Creation of DLP policies and procedures
- C. Encryption of data copied to flash drives
- D. Identification and classification of sensitive data

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 864

An IS auditor finds that the process for removing access for terminated employees is not documented. What is the MOST significant risk from this observation?

- A. Procedures may not align with best practices.
- B. HR records may not match system access.
- C. Unauthorized access cannot be identified.
- D. Access rights may not be removed in a timely manner.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 865

Which of the following scenarios would enable a forensic investigation?

- A. The suspected computer was rebooted, and the evidence log file was converted to a readable format for further analysis.
- B. The incident response team prepared a final report for the forensic investigator and deleted the original file securely to avoid further damage.
- C. The media in question was preserved using imaging, and chain of custody was documented according to the organization's incident response plan.
- D. Incident response team members extracted the logs showing the suspicious activity and added their notes before submitting for investigation.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 866

What is an IS auditor's BEST recommendation to management if a review of the incident management process finds multiple instances of incident tickets remaining open for an unusually long time?

- A. Implement reporting of key performance indicators (KPIs) for ticket closure.
- B. Increase the number of help desk staff to enable faster ticket closure.
- C. Manually review the identified tickets and mark as closed in the system.
- D. Configure the system to automatically close tickets after a defined period.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 867

An organization recently experienced a phishing attack that resulted in a breach of confidential information. Which of the following would be MOST relevant for an IS auditor to review when determining the root cause of the incident?

- A. Email configurations
- B. Simple mail transfer protocol (SMTP) logging
- C. Browser configurations
- D. Audit logging

Correct Answer: B

Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 868

Which of the following is MOST important to include in an organization's incident response plan to help prevent similar incidents from happening in the future?

- A. Documentation of incident details
- B. Incident closure procedures
- C. Containment and neutralization actions
- D. Post-incident review

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 869

An IS auditor reviewing security incident processes realizes incidents are resolved and closed, but root causes are not investigated. Which of the following should be the MAJOR concern with this situation?

- A. Abuses by employees have not been reported.
- B. Vulnerabilities have not been properly addressed.
- C. Security incident policies are out of date.
- D. Lessons learned have not been properly documented.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 870

Which of the following is the BEST indication of an effective incident management process?

- A. Percentage of incidents where root cause has been identified
- B. Percentage of incidents closed without escalation
- C. Number of calls to the help desk
- D. Number of incidents reviewed by the IT management

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 871

Which of the following metrics would be MOST helpful to an IS auditor in evaluating an organization's security incident response management capability?

- A. Number of business interruptions due to IT security incidents per year.
- B. Number of IT security incidents reported per month
- C. Number of malware infections in business applications detected per day.
- D. Number of alerts generated by intrusion detection systems (IDS) per minute.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 872

The MAIN reason an organization's incident management procedures should include a post-incident review is to:

- A. ensure evidence is collected for possible post-event litigation.
- B. take appropriate action when procedures are not followed.
- C. enable better reporting for executives and the audit committee.
- D. improve processes by learning from identified weaknesses.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 873

Which of the following is MOST important for the improvement of an organization's incident response processes?

- A. Post-event reviews by the incident response team
- B. Regular upgrades to incident management software
- C. Ongoing incident response training for users
- D. Periodic walk-through of incident response procedures

Correct Answer: A
Explanation

Explanation/Reference:

QUESTION 874

An IS auditor has discovered that unauthorized customer management software was installed on a workstation. The auditor determines the software has been uploading customer data to an external party. Which of the following is the IS auditor's BEST course of action?

- A. Review other workstations to determine the extent of the incident.
- B. Determine the number of customer records that were uploaded.
- C. Notify the incident response team.
- D. Present the issue at the next audit progress meeting.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 875

The PRIMARY reason an IS department should analyze past incidents and problems is to:

- A. determine if all incidents and problems are reported.
- B. assign responsibility for problems.
- C. assess help desk performance.
- D. identify the causes of recurring incidents and problems.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 876

Which of the following is the MAIN purpose of implementing an incident response process?

- A. Provide substantial audit-trail evidence.
- B. Assign roles and responsibilities.
- C. Comply with policies and procedures.
- D. Manage impact due to breaches.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 877

An IS auditor learns a server administration team regularly applies workarounds to address repeated failures of critical data processing services. Which of the following would BEST enable the organization to resolve this issue?

- A. Service level management
- B. Change management
- C. Problem management
- D. Incident management

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 878

When an intrusion into an organization's network is detected, which of the following should be performed FIRST?

- A. Block all compromised network nodes.
- B. Protect information in the compromised systems.
- C. Develop a response to the incident.
- D. Identify nodes that have been compromised.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 879

Which of the following is MOST important for an IS auditor to consider when reviewing the effectiveness of an incident response program?

- A. Incidents are categorized according to industry standards.
- B. Lessons learned are incorporated into incident response processes.
- C. Incidents are escalated to senior management in a timely manner.
- D. The plan is reviewed and updated annually.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 880

Which of the following is the GREATEST benefit of implementing an incident management process?

- A. Opportunity for frequent reassessment of incidents
- B. Reduction in security threats
- C. Reduction in the business impact of incidents
- D. Reduction of costs by the efficient use of resources

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 881

Both statistical and nonstatistical sampling techniques:

- A. permit the auditor to quantify the probability of error.
- B. permit the auditor to quantify and fix the level of risk.
- C. require judgment when defining population characteristics.
- D. provide each item an equal opportunity of being selected.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 882

Cross-site scripting (XSS) attacks are BEST prevented through:

- A. use of common industry frameworks.
- B. secure coding practices.
- C. application firewall policy settings.
- D. a three-tier web architecture.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 883

The PRIMARY advantage of object-oriented technology is enhanced:

- A. efficiency due to the re-use of elements of logic.
- B. management of sequential program execution for data access.
- C. management of a restricted variety of data types for a data object.
- D. grouping of objects into methods for data access.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 884

Which of the following would BEST facilitate the detection of internal fraud perpetrated by an individual?

- A. Corporate fraud hotline
- B. Segregation of duties
- C. Mandatory leave
- D. Flexible time

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 885

Which of the following is the PRIMARY advantage of using virtualization technology for corporate applications?

- A. Better utilization of resources
- B. Stronger data security
- C. Increased application performance
- D. Improved disaster recovery

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 886

Which of the following is the MOST effective control for a utility program?

- A. Renaming the versions in the programmers' libraries
- B. Installing the program on a separate server
- C. Storing the program in a production library
- D. Allowing only authorized personnel to use the program

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 887

The control that MOST effectively addresses the risk of piggybacking/tailgating into a restricted area without a dead man door is:

- A. using biometric door locks.
- B. security awareness training.
- C. requiring employees to wear ID badges.
- D. using two-factor authentication.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 888

Which of the following provides the MOST assurance that a newly developed web application does not have IT security issues?

- A. Server hardening
- B. Business impact analysis (BIA)
- C. Application whitelisting
- D. Penetration testing

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 889

An airline's online booking system uses an automated script that checks whether fares are within the defined threshold of what is reasonable before the fares are displayed on the website. Which type of control is in place?

- A. Compensating control
- B. Preventive control
- C. Detective control
- D. Corrective control

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 890

Which of the following features can be provided only by asymmetric encryption?

- A. 128-bit key length
- B. Information privacy
- C. Data confidentiality
- D. Nonrepudiation

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 891

Which of the following is the MOST effective way to assess whether an outsourcer's controls are following the service level agreement (SLA)?

- A. Perform an onsite review of the outsourcer.
- B. Review the outsourcer's monthly service reports.
- C. Perform a review of penalty clauses for non-performance.
- D. Review an internal audit report from the outsourcer's auditor.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 892

Which of the following BEST indicates the effectiveness of an organization's risk management program?

- A. Control risk is minimized.
- B. Inherent risk is eliminated.

- C. Residual risk is minimized.
- D. Overall risk is quantified.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 893

A retirement system verifies that the field for employee status has either a value of A (for active) or R (for retired). This is an example of which type of check?

- A. Validity
- B. Existence
- C. Limit
- D. Completeness

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 894

Which of the following controls would BEST decrease the exposure if a password is compromised?

- A. Passwords are masked.
- B. Passwords are encrypted.
- C. Passwords have format restrictions.
- D. Password changes are forced periodically.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 895

The BEST data backup strategy for mobile users is to:

- A. synchronize data directories automatically over the network.
- B. have them regularly back up data directories onto CD and courier the backups to the head office.
- C. mirror all data to a portable storage device.
- D. have them regularly go to branch offices to perform backups.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 896

Which of the following would BEST enable effective IT resource management?

- A. Assessing the risk associated with IT resources
- B. Outsourcing IT processes and activities
- C. Establishing business priorities
- D. Automating business processes

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 897

Digital signatures are an effective control method for information exchange over an insecure network because they:

- A. enable nonrepudiation.
- B. are under the sole custody of the receiver.
- C. are constant over time.
- D. authenticate the user biometrically.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 898

Which of the following BEST determines if a batch update job was completed?

- A. Reviewing a copy of the script for the job
- B. Verifying the timestamp from the job log
- C. Testing a sample of transactions to confirm updates were applied
- D. Obtaining process owner confirmation that the job was completed

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 899

Which of the following would be MOST important to include in a data security policy to adequately manage the privacy of customer information?

- A. Information classification criteria
- B. Encryption technology
- C. Backup strategy
- D. Data ownership

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 900

Which of the following is the MOST important reason to periodically review data that has already been classified?

- A. The associated risk may change over time.
- B. Additional data may have been added to the inventory.
- C. Older data may need to be archived on removable media.
- D. The classification nomenclature has changed.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 1

Which of the following is the MOST effective control to ensure electronic records beyond their retention periods are deleted from IT systems?

- A. Review the record retention register regularly to initiate data deletion.
- B. Build in system logic to trigger data deletion at predefined times.
- C. Perform a sample check of current data against the retention schedule.
- D. Execute all data deletions at a predefined month during the year.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 2

Which of the following management decisions presents the GREATEST risk associated with data leakage?

- A. Security awareness training is not provided to staff.
- B. There is no requirement for desktops to be encrypted.
- C. Security policies have not been updated in the past year.
- D. Staff are allowed to work remotely.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 3

Capacity management enables organizations to:

- A. establish the capacity of network communication links.
- B. determine business transaction volumes.
- C. forecast technology trends.
- D. identify the extent to which components need to be upgraded.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 4

The lack of which of the following represents the GREATEST risk to the quality of developed software?

- A. Code reviews
- B. Periodic internal audits
- C. Load testing
- D. An enterprise architecture

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 5

An enterprise receiving email should have procedures to control:

- A. insufficient end-points.
- B. unsolicited executable code.
- C. outdated protocols.
- D. insufficient connectivity.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 6

Which of the following provides the BEST audit evidence that a firewall is configured in compliance with the organization's security policy?

- A. Analyzing how the configuration changes are performed
- B. Performing penetration testing
- C. Analyzing log files
- D. Reviewing the rule base

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 7

Nonrepudiation of the client for e-commerce transactions is accomplished through which of the following control mechanisms?

- A. Password security
- B. Internet protocol (IP) address verification
- C. Public key infrastructure (PKI)
- D. Secure Sockets Layer (SSL)

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 8

A sales representative is reviewing the organization's feedback blog and gets redirected to a site that sells illegal prescription drugs. The blog site is MOST likely susceptible to which of the following types of attacks?

- A. Directory harvesting
- B. SQL injection
- C. Cross-site scripting
- D. Phishing attack.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 9

To ensure the integrity of a recovered database, which of the following would be MOST useful?

- A. Before-and-after transaction images
- B. Database defragmentation tools
- C. A copy of the data dictionary
- D. Application transaction logs

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 10

Reorganization of databases is undertaken PRIMARILY to:

- A. reduce backout and recovery times.
- B. eliminate duplicates and perform data backup.
- C. reduce simultaneous update time and index validation.
- D. improve data access and retrieval times.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 11

The PRIMARY benefit of using secure shell (SSH) to access a server on a network is that it:

- A. provides better session reliability.
- B. prevents man-in-the-middle attacks.
- C. provides confidentiality of transmitted data.
- D. facilitates communication across platforms.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 12

Which of the following would BEST detect that a distributed-denial-of-service attack (DDoS) is occurring?

- A. Server crashes
- B. Automated monitoring of logs
- C. Penetration testing
- D. Customer service complaints

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 13

Due to the cost restraints, a company defers the replacement of hardware supporting core application. Which of the following represents the GREATEST risk?

- A. Maintenance costs may rise.

- B. Future upgrades may not be possible.
- C. Systems availability may suffer.
- D. Eventual replacement may be more expensive.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 14

Which of the following is the BEST source of information for assessing the effectiveness of IT process monitoring?

- A. Participative management techniques
- B. Quality assurance (QA) reviews
- C. Performance data
- D. Real-time audit software

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 15

Attribute sampling is BEST suited to estimate:

- A. compliance with approved procedures.
- B. the true monetary value of a population.
- C. the total error amount in the population.
- D. whether a recorded balance is within limits of materiality.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 16

Which of the following methods should be used to effectively erase sensitive data from portable storage devices that are to be reused?

- A. Formatting the portable device
- B. Using media sanitization software
- C. Overwriting the sensitive data
- D. Exposing the portable device to a magnetic field

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 17

A database audit reveals an issue with the way data ownership for client data is defined. Which of the following roles should be accountable for this finding?

- A. Business management
- B. Database administrator (DBA)
- C. Information security management
- D. Privacy manager

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 18

Which of the following would be the MOST appropriate reason for an organization to purchase fault-tolerant hardware?

- A. Reducing hardware maintenance costs.
- B. Improving system performance.
- C. Minimizing business loss.
- D. Compensating for the lack of contingency planning

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 19

Which of the following is the PRIMARY purpose of documenting and approving an information security policy?

- A. To communicate management's intent for securing the organization's information assets
- B. To mitigate the organization's information security risk to an acceptable level
- C. To ensure awareness of disciplinary procedures for security breaches by authorized users
- D. To determine the best approach for implementing information security within the organization

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 20

Which of the following is the BEST method for uncovering shadow IT within an organization?

- A. Analyze help desk tickets.
- B. Review secondary approval thresholds.
- C. Use a cloud access security broker (CASB).
- D. Review business processes.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 21

Which of the following is the BEST reason to perform root cause analysis after a critical server failure?

- A. To enable appropriate corrective measures
- B. To enable the gathering of system availability data
- C. To enable timely follow-up audits
- D. To enable the optimization of IT investments

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 22

Which of the following would help determine the maturity of an information security awareness program?

- A. A review of the annual penetration test results
- B. A network vulnerability assessment
- C. A simulated social engineering test
- D. A gap assessment against an established model

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 23

A user of a telephone banking system has forgotten his personal identification number (PIN). After the user has been authenticated, the BEST method of issuing a new PIN is to have:

- A. the user enter a new PIN twice.
- B. banking personnel verbally assign a new PIN.
- C. a randomly generated PIN communicated by banking personnel.
- D. banking personnel assign the user a new PIN via email.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 24

Privileged account access is required to start an ad hoc batch job. Which of the following would MOST effectively detect unauthorized job execution?

- A. Requiring manual approval by an authorized user
- B. Executing the job through two-factor authentication
- C. Introducing job execution request procedures
- D. Reconciling user activity logs against authorizations

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 25

Due to the small size of the payroll department, an organization is unable to segregate the employee setup and payroll processing functions. Which of the following would be the BEST compensating control for the lack of segregation of duties?

- A. An independent payroll disbursement review is conducted.
- B. The system is configured to require secondary approval for changes to the employee master file.
- C. A review is conducted to verify that terminated employees are removed from the employee master file.
- D. A payroll variance report is reviewed for anomalies every pay period.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 26

Which of the following is the MOST critical step prior to performing a network penetration test?

- A. Informing management of the potential risk involved with penetration testing
- B. Identifying a scanning tool for use in identifying vulnerabilities
- C. Communicating the location of the penetration test targets to management
- D. Reviewing the results of previous penetration tests

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 27

Which of the following is the MOST significant concern when backup tapes are encrypted?

- A. Loss of the encryption key
- B. Lack of physical security over the tapes
- C. Incompatibility with future software versions
- D. Inaccurate data due to encryption processing

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 28

Based on the guidance of internal audit, an IT steering committee is considering the use of a balanced scorecard to evaluate its project management process. Which of the following is the GREATEST advantage to using this approach?

- A. Project schedule and budget management will improve.
- B. Performance is measured from different perspectives.
- C. Information is provided in a consistent and timely manner.
- D. Project will be prioritized based on value.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 29

The quality assurance (QA) function should be prevented from:

- A. developing naming conventions.
- B. establishing analysis techniques.
- C. amending review procedures.
- D. changing programs for business functions.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 30

Which of the following provides the GREATEST assurance that any confidential information on a disk is no longer accessible but the device is still usable by other internal users?

- A. Reformatting the disk
- B. Erasing the disk
- C. Degaussing the disk
- D. Password-protecting the disk

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 31

The demilitarized zone (DMZ) is the part of a network where servers that are placed are:

- A. running internal department applications.
- B. running mission-critical, non-web applications.
- C. interacting with the public Internet.
- D. external to the organization.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 32

An IS auditor is unable to directly test privacy controls for a client's cloud-based application. The MOST effective alternative to direct testing is to review:

- A. the provider's internal audit reports.
- B. the provider's statement of assurance.
- C. formal privacy certification.
- D. independent audit reports.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 33

An organization has installed blade server technology in its data center. To determine whether higher cooling demands are maintained, which of the following should the IS auditor review?

- A. Ventilation systems
- B. Uninterruptible power supply (UPS) systems
- C. Air conditioning capacity
- D. Duct maintenance

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 34

An employee loses a mobile device resulting in loss of sensitive corporate data. Which of the following would have BEST prevented data leakage?

- A. Awareness training for mobile device users
- B. Data encryption on the mobile device
- C. The triggering of remote data wipe capabilities
- D. Complex password policy for mobile devices

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 35

When physical destruction is not practical, which of the following is the MOST effective means of disposing of sensitive data on a hard disk?

- A. Recycling the disk
- B. Reformatting
- C. Deleting files sequentially
- D. Overwriting multiple times

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 36

Which of the following components of a scheduling tool BEST prevents job failures due to insufficient system resources?

- A. Job dependencies
- B. Delayed job starts
- C. Exception handling
- D. Error alerts

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 37

Which of the following is the MOST effective control for emergency changes to application programs?

- A. Processing the change through change control with review of the change the following day
- B. Keeping a sealed envelope containing a password that operators can use to make emergency changes
- C. Periodically checking the application program libraries to detect whether unauthorized changes have been made
- D. Preparing and approving program change forms before the changes are made

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 38

Which of the following controls would BEST ensure that payroll system rate changes are valid?

- A. Only a payroll department manager can input the new rate.
- B. Rate changes require visual verification before acceptance.
- C. Rate changes must be entered twice to ensure that they are entered correctly.
- D. Rate changes are reported to and independently verified by a manager.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 39

Which of the following BEST enables timely detection of changes in the IT environment to support informed decision making by management?

- A. Continuous monitoring
- B. Sampling checks on high-risk areas
- C. Change management reports
- D. Established key risk indicators (KRIs)

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 40

Which of the following is BEST for providing uninterrupted services?

- A. Snapshots
- B. Differential backup
- C. Televaulting
- D. Mirroring

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 41

An organization globally distributes a free phone application that includes a module to gather and report user information. The application includes a privacy notice alerting users to the data gathering. Which of the following presents the GREATEST risk?

- A. The data gathering notice is available in only one language.
- B. There is no framework to delete personal data.
- C. There may be a backlash among users when the data gathering is revealed.
- D. The data is not properly encrypted on the application server.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 42

Which of the following metrics would BEST measure the agility of an organization's IT function?

- A. Average time to turn strategic IT objectives into an agreed upon and approved initiative
- B. Average number of learning and training hours per IT staff member
- C. Frequency of security assessments against the most recent standards and guidelines
- D. Percentage of staff with sufficient IT-related skills for the competency required of their roles.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 43

Which of the following should be performed FIRST when preparing to deploy a major upgrade to a critical online application?

- A. Update the disaster recovery process.
- B. Update the business impact analysis (BIA).
- C. Test the rollback process.
- D. Review data backup procedures.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 44

Which of the following is the BEST detective control for a job scheduling process involving data transmission?

- A. Metrics denoting the volume of monthly job failures are reported and reviewed by senior management.
- B. Job failure alerts are automatically generated and routed to support personnel.
- C. Jobs are scheduled and a log of this activity is retained for subsequent review.
- D. Jobs are scheduled to be completed daily and data is transmitted using a secure File Transfer Protocol (FTP).

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 45

Which of the following is the MOST important consideration when deploying closed-circuit television (CCTV) systems that use wireless communication links to transmit images between cameras and a receiver?

- A. Encryption of transmissions
- B. Monitoring by security guards
- C. Retention period of recordings
- D. Strategic placement of cameras

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 46

An organization is running servers with critical business applications that are in an area subject to frequent but brief power outages. Knowledge of which of the following would allow the organization's management to monitor the ongoing adequacy of the uninterruptible power supply (UPS)?

- A. Duration and interval of the power outages
- B. Business impact of server downtime
- C. Number of servers supported by the UPS
- D. Mean time to recover servers after failure

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 47

Which of the following is an example of audit risk?

- A. Audit work may be lost due to a malware attack.
- B. Management may disagree with audit conclusions.
- C. Sampling methods may not detect a material error.
- D. Newer auditors may require additional supervision and training.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 48

The GREATEST risk of database denormalization is:

- A. decreased performance.
- B. loss of data confidentiality.
- C. loss of database integrity.
- D. incorrect metadata.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 49

Which of the following provides the MOST comprehensive description of IT's role in an organization?

- A. IT organizational chart
- B. IT project portfolio
- C. IT charter
- D. IT job descriptions

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 50

Which of the following would MOST effectively aid executive management in achieving IT and business alignment?

- A. Risk assessment

- B. Value delivery assessment
- C. Balanced scorecard
- D. Performance measurement

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 51

Which of the following is BEST enabled by following a configuration management process for new applications?

- A. Deploying approved emergency changes to production
- B. Ensuring proper testing of code before deployment
- C. Managing successful implementation of acquired software
- D. Maintaining adequate control over changes to production

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 52

Loading of illegal software packages onto a network by an employee is MOST effectively detected by:

- A. diskless workstations.
- B. regular scanning of hard drives
- C. maintaining current antivirus software.
- D. logging of activity on network drives.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 53

Effective IT governance requires organizational structures and processes to ensure that:

- A. the organization's strategies and objectives extend the IT strategy.
- B. the business strategy is derived from an IT strategy.
- C. IT governance is separate and distinct from the overall governance.
- D. the IT strategy extends the organization's strategies and objectives.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets
Effective IT governance requires that board and executive management extend governance to IT and provide the leadership, organizational structures and processes that ensure that the organization's IT sustains and extends the organization's strategies and objectives, and that the strategy is aligned with business strategy. Choice A is incorrect because it is the IT strategy that extends the organizational objectives, not the opposite. IT governance is not an isolated discipline; it must become an integral part of the overall enterprise governance.

QUESTION 54

Which of the following is the MOST important element for the successful implementation of IT governance?

- A. Implementing an IT scorecard
- B. Identifying organizational strategies
- C. Performing a risk assessment
- D. Creating a formal security policy

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets
The key objective of an IT governance program is to support the business, thus the identification of organizational strategies is necessary to ensure alignment between IT and corporate governance. Without identification of organizational strategies, the remaining choices-even if implemented-would be ineffective.

QUESTION 55

The MAJOR consideration for an IS auditor reviewing an organization's IT project portfolio is the:

- A. IT budget.
- B. existing IT environment.
- C. business plan.
- D. investment plan.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets
One of the most important reasons for which projects get funded is how well a project meets an organization's strategic objectives. Portfolio management takes a holistic view of a company's overall IT strategy. IT strategy should be aligned with the business strategy and, hence, reviewing the business plan should be the major consideration. Choices A, B and D are important but secondary to the importance of reviewing the business plan,

QUESTION 56

When implementing an IT governance framework in an organization the MOST important objective is:

- A. IT alignment with the business.
- B. accountability.
- C. value realization with IT.
- D. enhancing the return on IT investments.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The goals of IT governance are to improve IT performance, to deliver optimum business value and to ensure regulatory compliance. The key practice in support of these goals is the strategic alignment of IT with the business (choice A). To achieve alignment, all other choices need to be tied to business practices and strategies.

QUESTION 57

The ultimate purpose of IT governance is to:

- A. encourage optimal use of IT.
- B. reduce IT costs.
- C. decentralize IT resources across the organization.
- D. centralize control of IT.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

IT governance is intended to specify the combination of decision rights and accountability that is best for the enterprise. It is different for every enterprise.

Reducing IT costs may not be the best IT governance outcome

for an enterprise. Decentralizing IT resources across the organization is not always desired, although it may be desired in a decentralized environment.

Centralizing control of IT is not always desired. An example of where it might be desired is an enterprise desiring a single point of customer contact.

QUESTION 58

What is the lowest level of the IT governance maturity model where an IT balanced scorecard exists?

- A. Repeatable but Intuitive
- B. Defined
- C. Managed and Measurable
- D. Optimized

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Defined (level 3) is the lowest level at which an IT balanced scorecard is defined.

QUESTION 59

Responsibility for the governance of IT should rest with the:

- A. IT strategy committee.
- B. chief information officer (CIO).
- C. audit committee.
- D. board of directors.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Governance is the set of responsibilities and practices exercised by the board and executive management with the goal of providing strategic direction, ensuring that objectives are achieved, ascertaining that risks are managed appropriately and verifying that the enterprise's resources are used responsibly. The audit committee, the chief information officer (CIO) and the IT strategy committee all play a significant role in the successful implementation of IT governance within an organization, but the ultimate accountability resides with the board of directors.

QUESTION 60

An IS auditor identifies that reports on product profitability produced by an organization's finance and marketing departments give different results. Further investigation reveals that the product definition being used by the two departments is different. What should the IS auditor recommend?

- A. User acceptance testing (UAT) occur for all reports before release into production
- B. Organizational data governance practices be put in place
- C. Standard software tools be used for report development
- D. Management sign-off on requirements for new reports

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

This choice directly addresses the problem. An organization wide approach is needed to achieve effective management of data assets. This includes enforcing standard definitions of data elements, which is part of a data governance initiative. The other choices, while sound development practices, do not address the root cause of the problem described.

QUESTION 61

From a control perspective, the key element in job descriptions is that they:

- A. provide instructions on how to do the job and define authority.
- B. are current, documented and readily available to the employee.
- C. communicate management's specific job performance expectations.
- D. establish responsibility and accountability for the employee's actions.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

From a control perspective, a job description should establish responsibility and accountability. This will aid in ensuring that users are given system access in accordance with their defined job responsibilities. The other choices are not directly related to controls. Providing instructions on how to do the job and defining authority addresses the managerial and procedural aspects of the job. It is important that job descriptions are current, documented and readily available to the employee, but this in itself is not a control. Communication of management's specific expectations for job performance outlines the standard of performance and would not necessarily include controls.

QUESTION 62

Which of the following would BEST provide assurance of the integrity of new staff?

- A. background screening
- B. References
- C. Bonding
- D. Qualifications listed on a resume

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A background screening is the primary method for assuring the integrity of a prospective staff member. References are important and would need to be verified, but they are not as reliable as background screening. Bonding is directed at due-diligence compliance, not at integrity, and qualifications listed on a resume may not be accurate.

QUESTION 63

When an employee is terminated from service, the MOST important action is to:

- A. hand over all of the employee's files to another designated employee.
- B. complete a backup of the employee's work.
- C. notify other employees of the termination.
- D. disable the employee's logical access.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

There is a probability that a terminated employee may misuse access rights; therefore, disabling the terminated employee's logical access is the most important action to take. All the work of the terminated employee needs to be handed over to a designated employee; however, this should be performed after implementing choice D. All the work of the terminated employee needs to be backed up and the employees need to be notified of the termination of the employee, but this should not precede the action in choice D.

QUESTION 64

Many organizations require an employee to take a mandatory vacation (holiday) of a week or more to:

- A. ensure the employee maintains a good quality of life, which will lead to greater productivity.
- B. reduce the opportunity for an employee to commit an improper or illegal act.
- C. provide proper cross-training for another employee.
- D. eliminate the potential disruption caused when an employee takes vacation one day at a time.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Required vacations/holidays of a week or more in duration in which someone other than the regular employee performs the job function is often mandatory for sensitive positions, as this reduces the opportunity to commit improper or illegal acts. During this time, it may be possible to discover any fraudulent activity that was taking place. Choices A, C and D could all be organizational benefits from a mandatory vacation policy, but they are not the reason why the policy is established.

QUESTION 65

A local area network (LAN) administrator normally would be restricted from:

- A. having end-user responsibilities.
- B. reporting to the end-user manager
- C. having programming responsibilities.
- D. being responsible for LAN security administration.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A LAN administrator should not have programming responsibilities but may have end-user responsibilities. The LAN administrator may report to the director of the IPF or, in a decentralized operation, to the end-user manager. In small organizations, the LAN administrator may also be responsible for security administration over the LAN.

QUESTION 66

A long-term IS employee with a strong technical background and broad managerial experience has applied for a vacant position in the IS audit department. Determining whether to hire this individual for this position should be based on the individual's experience and:

- A. length of service, since this will help ensure technical competence.
- B. age, as training in audit techniques may be impractical.
- C. IS knowledge, since this will bring enhanced credibility to the audit function.
- D. ability, as an IS auditor, to be independent of existing IS relationships.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Independence should be continually assessed by the auditor and management. This assessment should consider such factors as changes in personal relationships, financial interests, and prior job assignments and responsibilities. The fact that the employee has worked in IS for many years may not in itself ensure credibility. The audit department's needs should be defined and any candidate should be evaluated against those requirements. The length of service will not ensure technical competency. Evaluating an individual's qualifications based on the age of the individual is not a good criterion and is illegal in many parts of the world.

QUESTION 67

An IS auditor should be concerned when a telecommunication analyst:

- A. monitors systems performance and tracks problems resulting from program changes.
- B. reviews network load requirements in terms of current and future transaction volumes.
- C. assesses the impact of the network load on terminal response times and network data transfer rates.
- D. recommends network balancing procedures and improvements.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The responsibilities of a telecommunications analyst include reviewing network load requirements in terms of current and future transaction volumes (choice B), assessing the impact of network load or terminal response times and network data transfer rates (choice C), and recommending network balancing procedures and improvements (choice D). Monitoring systems performance and tracking problems as a result of program changes (choice A) would put the analyst in a self-monitoring role.

QUESTION 68

When segregation of duties concerns exists between IT support staff and end users, what would be suitable compensating control?

- A. Restricting physical access to computing equipment
- B. Reviewing transaction and application logs
- C. Performing background checks prior to hiring IT staff
- D. Locking user sessions after a specified period of inactivity

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Only reviewing transaction and application logs directly addresses the threat posed by poor segregation of duties. The review is a means of detecting inappropriate behavior and also discourages abuse, because people who may otherwise be tempted to exploit the situation are aware of the likelihood of being caught. Inadequate segregation of duties is more likely to be exploited via logical access to data and computing

resources rather than physical access. Choice C is a useful control to ensure IT staff are trustworthy and competent but does not directly address the lack of an optimal segregation of duties. Choice D acts to prevent unauthorized users from gaining system access, but the issue of a lack of segregation of duties is more the misuse (deliberately or inadvertently) of access privileges that have officially been granted.

QUESTION 69

An IS auditor reviewing an organization that uses cross-training practices should assess the risk of:

- A. dependency on a single person.
- B. inadequate succession planning.
- C. one person knowing all parts of a system.
- D. a disruption of operations.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Cross-training is a process of training more than one individual to perform a specific job or procedure. This practice helps decrease the dependence on a single person and assists in succession planning. This provides for the backup of personnel in the event of an absence and, thereby, provides for the continuity of operations. However, in using this approach, it is prudent to have first assessed the risk of any person knowing all parts of a system and the related potential exposures. Cross-training reduces the risks addressed in choices A, B and D.

QUESTION 70

Which of the following controls would an IS auditor look for in an environment where duties cannot be appropriately segregated?

- A. Overlapping controls
- B. Boundary controls
- C. Access controls
- D. Compensating controls

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Compensating controls are internal controls that are intended to reduce the risk of an existing or potential control weakness that may arise when duties cannot be appropriately segregated. Overlapping controls are two controls addressing the same control objective or exposure. Since primary controls cannot be achieved when duties cannot or are not appropriately segregated, it is difficult to install overlapping controls. Boundary controls establish the interface between the would-be user of a computer system and the computer system itself, and are individual-based, not role-based, controls. Access controls for resources are based on individuals and not on roles.

QUESTION 71

Which of the following reduces the potential impact of social engineering attacks?

- A. Compliance with regulatory requirements
- B. Promoting ethical understanding
- C. Security awareness programs
- D. Effective performance incentives

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Because social engineering is based on deception of the user, the best countermeasure or defense is a security awareness program. The other choices are not user-focused.

QUESTION 72

Which of the following activities performed by a database administrator (DBA) should be performed by a different person?

- A. Deleting database activity logs
- B. Implementing database optimization tools
- C. Monitoring database usage
- D. Defining backup and recovery procedures

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Since database activity logs record activities performed by the database administrator (DBA), deleting them should be performed by an individual other than the DBA. This is a compensating control to aid in ensuring an appropriate segregation of duties and is associated with the DBA's role. A DBA should perform the other activities as part of the normal operations.

QUESTION 73

To gain an understanding of the effectiveness of an organization's planning and management of investments in IT assets, an IS auditor should review the:

- A. enterprise data model.
- B. IT balanced scorecard (BSC).
- C. IT organizational structure.
- D. historical financial statements.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The IT balanced scorecard (BSC) is a tool that provides the bridge between IT objectives and business objectives by supplementing the traditional financial evaluation with measures to evaluate customer satisfaction, internal processes and the ability to innovate. An enterprise data model is a document defining the data structure of an organization and how data interrelate. It is useful, but it does not provide information on investments. The IT organizational structure provides an overview of the functional and reporting relationships in an IT entity. Historical financial statements do not provide information about planning and lack sufficient detail to enable one to fully understand management's activities regarding IT assets. Past costs do not necessarily reflect value, and assets such as data are not represented on the books of accounts.

QUESTION 74

Which of the following is the BEST performance criterion for evaluating the adequacy of an organization's security awareness training?

- A. Senior management is aware of critical information assets and demonstrates an adequate concern for their protection.
- B. Job descriptions contain clear statements of accountability for information security.
- C. In accordance with the degree of risk and business impact, there is adequate funding for security efforts.
- D. No actual incidents have occurred that have caused a loss or a public embarrassment.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Inclusion in job descriptions of security responsibilities is a form of security training and helps ensure that staff and management are aware of their roles with respect to information security. The other three choices are not criterion for evaluating security awareness training. Awareness is a criterion for evaluating the importance that senior management attaches to information assets and their protection. Funding is a criterion that aids in evaluating whether security vulnerabilities are being addressed, while the number of incidents that have occurred is a criterion for evaluating the adequacy of the risk management program.

QUESTION 75

Which of the following is a risk of cross-training?

- A. Increases the dependence on one employee
- B. Does not assist in succession planning
- C. One employee may know all parts of a system
- D. Does not help in achieving a continuity of operations

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When cross-training, it would be prudent to first assess the risk of any person knowing all parts of a system and what exposures this may cause. Cross-training has the advantage of decreasing dependence on one employee and, hence, can be part of succession planning. It also provides backup for personnel in the event of absence for any reason and thereby facilitates the continuity of operations.

QUESTION 76

Which of the following is normally a responsibility of the chief security officer (CSO)?

- A. Periodically reviewing and evaluating the security policy
- B. Executing user application and software testing and evaluation
- C. Granting and revoking user access to IT resources
- D. Approving access to data and applications

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The role of a chief security officer (CSO) is to ensure that the corporate security policy and controls are adequate to prevent unauthorized access to the company assets, including data, programs and equipment. User application and other software testing and evaluation normally are the responsibility of the staff assigned

to development and maintenance. Granting and revoking access to IT resources is usually a function of network or database administrators. Approval of access to data and applications is the duty of the data owner.

QUESTION 77

To support an organization's goals, an IS department should have:

- A. a low-cost philosophy.
- B. long- and short-range plans.
- C. leading-edge technology.
- D. plans to acquire new hardware and software.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

To ensure its contribution to the realization of an organization's overall goals, the IS department should have long- and short-range plans that are consistent with the organization's broader plans for attaining its goals. Choices A and C are objectives, and plans would be needed to delineate how each of the objectives would be achieved. Choice D could be a part of the overall plan but would be required only if hardware or software is needed to achieve the organizational goals.

QUESTION 78

In reviewing the IS short-range (tactical) plan, an IS auditor should determine whether:

- A. there is an integration of IS and business staffs within projects.
- B. there is a clear definition of the IS mission and vision.
- C. a strategic information technology planning methodology is in place.
- D. the plan correlates business objectives to IS goals and objectives.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The integration of IS and business staff in projects is an operational issue and should be considered while reviewing the short-range plan. A strategic plan would provide a framework for the IS short-range plan.

Choices B, C and D are areas covered by a strategic plan.

QUESTION 79

Which of the following would an IS auditor consider the MOST relevant to short-term planning for an IS department?

- A. Allocating resources
- B. Keeping current with technology advances
- C. Conducting control self-assessment
- D. Evaluating hardware needs

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The IS department should specifically consider the manner in which resources are allocated in the short term. Investments in IT need to be aligned with top management strategies, rather than focusing on technology for technology's sake. Conducting control self-assessments and evaluating hardware needs are not as critical as allocating resources during short-term planning for the IS department.

QUESTION 80

Which of the following goals would you expect to find in an organization's strategic plan?

- A. Test a new accounting package.
- B. Perform an evaluation of information technology needs.
- C. Implement a new project planning system within the next 12 months.
- D. Become the supplier of choice for the product offered.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Strategic planning sets corporate or departmental objectives into motion. Comprehensive planning helps ensure an effective and efficient organization. Strategic

planning is time- and project-oriented, but also must address and help determine priorities to meet business needs. Long- and short-range plans should be consistent with the organization's broader plans for attaining their goals. Choice D represents a business objective that is intended to focus the overall direction of the business and would thus be a part of the organization's strategic plan. The other choices are project-oriented and do not address business objectives.

QUESTION 81

Which of the following would an IS auditor consider to be the MOST important when evaluating an organization's IS strategy? That it:

- A. has been approved by line management.
- B. does not vary from the IS department's preliminary budget.
- C. complies with procurement procedures.
- D. supports the business objectives of the organization.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Strategic planning sets corporate or department objectives into motion. Both long-term and short-term strategic plans should be consistent with the organization's broader plans and business objectives for attaining these goals. Choice A is incorrect since line management prepared the plans.

QUESTION 82

An IS auditor reviewing an organization's IT strategic plan should FIRST review:

- A. the existing IT environment.
- B. the business plan.
- C. the present IT budget.
- D. current technology trends.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The IT strategic plan exists to support the organization's business plan. To evaluate the IT strategic plan, an IS auditor would first need to familiarize themselves with the business plan.

QUESTION 83

When reviewing IS strategies, an IS auditor can BEST assess whether IS strategy supports the organizations' business objectives by determining if IS:

- A. has all the personnel and equipment it needs.
- B. plans are consistent with management strategy.
- C. uses its equipment and personnel efficiently and effectively.
- D. has sufficient excess capacity to respond to changing directions.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Determining if the IS plan is consistent with management strategy relates IS/IT planning to business plans. Choices A, C and D are effective methods for determining the alignment of IS plans with business objectives and the organization's strategies.

QUESTION 84

In an organization, the responsibilities for IT security are clearly assigned and enforced and an IT security risk and impact analysis is consistently performed. This represents which level of ranking in the information security governance maturity model?

- A. Optimized
- B. Managed
- C. Defined
- D. Repeatable

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Boards of directors and executive management can use the information security governance maturity model to establish rankings for security in their organizations. The ranks are nonexistent, initial, repeatable, defined, managed and optimized. When the responsibilities for IT security in an organization are clearly assigned and enforced and an IT security risk and impact analysis is consistently performed, it is said to be 'managed and measurable.'

QUESTION 85

To aid management in achieving IT and business alignment, an IS auditor should recommend the use of:

- A. control self-assessments.
- B. a business impact analysis.
- C. an IT balanced scorecard.
- D. business process reengineering.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IT balanced scorecard (BSC) provides the bridge between IT objectives and business objectives by supplementing the traditional financial evaluation with measures to evaluate customer satisfaction, internal processes and the ability to innovate. Control self-assessment (CSA), business impact analysis (BIA) and business process reengineering (BPR) are insufficient to align IT with organizational objectives.

QUESTION 86

When reviewing the IT strategic planning process, an IS auditor should ensure that the plan:

- A. incorporates state of the art technology.
- B. addresses the required operational controls.
- C. articulates the IT mission and vision.
- D. specifies project management practices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The IT strategic plan must include a clear articulation of the IT mission and vision. The plan need not address the technology, operational controls or project management practices.

QUESTION 87

When developing a formal enterprise security program, the MOST critical success factor (CSF) would be the:

- A. establishment of a review board.
- B. creation of a security unit.
- C. effective support of an executive sponsor.
- D. selection of a security process owner.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The executive sponsor would be in charge of supporting the organization's strategic security program, and would aid in directing the organization's overall security management activities. Therefore, support by the executive level of management is the most critical success factor (CSF). None of the other choices are effective without visible sponsorship of top management.

QUESTION 88

When reviewing an organization's strategic IT plan an IS auditor should expect to find:

- A. an assessment of the fit of the organization's application portfolio with business objectives.
- B. actions to reduce hardware procurement cost.
- C. a listing of approved suppliers of IT contract resources.
- D. a description of the technical architecture for the organization's network perimeter security.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An assessment of how well an organization's application portfolio supports the organization's business objectives is a key component of the overall IT strategic planning process. This drives the demand side of IT planning and should convert into a set of strategic IT intentions. Further assessment can then be made of how well the overall IT organization, encompassing applications, infrastructure, services, management processes, etc., can support the business objectives. Operational efficiency initiatives belong to tactical planning, not strategic planning. The purpose of an IT strategic plan is to set out how IT will be used to achieve or support an organization's business objectives. A listing of approved suppliers of IT contract resources is a tactical rather than a strategic concern. An IT strategic plan would not normally include detail of a specific technical architecture.

QUESTION 89

The advantage of a bottom-up approach to the development of organizational policies is that the policies:

- A. are developed for the organization as a whole
- B. are more likely to be derived as a result of a risk assessment.
- C. will not conflict with overall corporate policy.
- D. ensure consistency across the organization.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A bottom-up approach begins by defining operational-level requirements and policies, which are derived and implemented as the result of risk assessments. Enterprise-level policies are subsequently developed based on a synthesis of existing operational policies. Choices A, C and D are advantages of a top-down approach for developing organizational policies. This approach ensures that the policies will not be in conflict with overall corporate policy and ensure consistency across the organization.

QUESTION 90

Which of the following is the GREATEST risk of an inadequate policy definition for ownership of data and systems?

- A. User management coordination does not exist.
- B. Specific user accountability cannot be established.
- C. Unauthorized users may have access to originate, modify or delete data.
- D. Audit recommendations may not be implemented.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Without a policy defining who has the responsibility for granting access to specific systems, there is an increased risk that one could gain (be given) system access when they should not have authorization. By assigning authority to grant access to specific users, there is a better chance that business objectives will be properly supported.

QUESTION 91

The PRIMARY objective of an audit of IT security policies is to ensure that:

- A. they are distributed and available to all staff.
- B. security and control policies support business and IT objectives.
- C. there is a published organizational chart with functional descriptions.
- D. duties are appropriately segregated.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Business orientation should be the main theme in implementing security. Hence, an IS audit of IT security policies should primarily focus on whether the IT and related security and control policies support business and IT objectives. Reviewing whether policies are available to all is an objective, but distribution does not ensure compliance. Availability of organizational charts with functional descriptions and segregation of duties might be included in the review, but are not the primary objective of an audit of security policies.

QUESTION 92

The rate of change in technology increases the importance of:

- A. outsourcing the IS function.
- B. implementing and enforcing good processes.
- C. hiring personnel willing to make a career within the organization.
- D. meeting user requirements.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Change requires that good change management processes be implemented and enforced. Outsourcing the IS function is not directly related to the rate of technological change. Personnel in a typical IS department are highly qualified and educated; usually they do not feel their jobs are at risk and are prepared to switch jobs frequently. Although meeting user requirements is important, it is not directly related to the rate of technological change in the IS environment.

QUESTION 93

An IS auditor finds that not all employees are aware of the enterprise's information security policy. The IS auditor should conclude that:

- A. this lack of knowledge may lead to unintentional disclosure of sensitive information.
- B. information security is not critical to all functions.
- C. IS audit should provide security training to the employees.
- D. the audit finding will cause management to provide continuous training to staff.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

All employees should be aware of the enterprise's information security policy to prevent unintentional disclosure of sensitive information. Training is a preventive control. Security awareness programs for employees can prevent unintentional disclosure of sensitive information to outsiders.

QUESTION 94

The development of an IS security policy is ultimately the responsibility of the:

- A. IS department.
- B. security committee.
- C. security administrator.
- D. board of directors.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Normally, the designing of an information systems security policy is the responsibility of top management or the board of directors. The IS department is responsible for the execution of the policy, having no authority in framing the policy. The security committee also functions within the broad security policy framed by the board of directors. The security administrator is responsible for implementing, monitoring and enforcing the security rules that management has established and authorized.

QUESTION 95

Which of the following programs would a sound information security policy MOST likely include to handle suspected intrusions?

- A. Response
- B. Correction
- C. Detection
- D. Monitoring

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A sound IS security policy will most likely outline a response program to handle suspected intrusions. Correction, detection and monitoring programs are all aspects of information security, but will not likely be included in an IS security policy statement.

QUESTION 96

Which of the following should be included in an organization's IS security policy?

- A. A list of key IT resources to be secured
- B. The basis for access authorization
- C. Identity of sensitive security features

D. Relevant software security features

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The security policy provides the broad framework of security, as laid down and approved by senior management. It includes a definition of those authorized to grant access and the basis for granting the access.

Choices A, B and C are more detailed than that which should be included in a policy.

QUESTION 97

Which of the following is the initial step in creating a firewall policy?

- A. A cost-benefit analysis of methods for securing the applications
- B. Identification of network applications to be externally accessed
- C. Identification of vulnerabilities associated with network applications to be externally accessed
- D. Creation of an applications traffic matrix showing protection methods

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Identification of the applications required across the network should be identified first. After identification, depending on the physical location of these applications in the network and the network model, the person in charge will be able to understand the need for, and possible methods of, controlling access to these applications. Identifying methods to protect against identified vulnerabilities and their comparative cost-benefit analysis is the third step. Having identified the applications, the next step is to identify vulnerabilities (weaknesses) associated with the network applications. The next step is to analyze the application traffic and create a matrix showing how each type of traffic will be protected.

QUESTION 98

The management of an organization has decided to establish a security awareness program. Which of the following would MOST likely be a part of the program?

- A. Utilization of an intrusion detection system to report incidents
- B. Mandating the use of passwords to access all software
- C. Installing an efficient user log system to track the actions of each user
- D. Training provided on a regular basis to all current and new employees

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Utilizing an intrusion detection system to report on incidents that occur is an implementation of a security program and is not effective in establishing a security awareness program. Choices B and C do not address awareness. Training is the only choice that is directed at security awareness.

QUESTION 99

Which of the following is MOST critical for the successful implementation and maintenance of a security policy?

- A. Assimilation of the framework and intent of a written security policy by all appropriate parties
- B. Management support and approval for the implementation and maintenance of a security policy
- C. Enforcement of security rules by providing punitive actions for any violation of security rules
- D. Stringent implementation, monitoring and enforcing of rules by the security officer through access control software

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Assimilation of the framework and intent of a written security policy by the users of the system is critical to the successful implementation and maintenance of the security policy. A good password system may exist, but if the users of the system keep passwords written on their desk, the password is of little value.

Management support and commitment is no doubt important, but for successful implementation and maintenance of security policy, educating the users on the importance of security is paramount. The stringent implementation, monitoring and enforcing of rules by the security officer through access control software, and provision for punitive actions for violation of security rules, is also required, along with the user's education on the importance of security.

QUESTION 100

A comprehensive and effective e-mail policy should address the issues of e-mail structure, policy enforcement, monitoring and:

- A. recovery.
- B. retention.
- C. rebuilding.
- D. reuse.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Besides being a good practice, laws and regulations may require that an organization keep information that has an impact on the financial statements. The prevalence of lawsuits in which e-mail communication is held in the same regard as the official form of classic 'paper' makes the retention of corporate e-mail a necessity. All e-mail generated on an organization's hardware is the property of the organization, and an e-mail policy should address the retention of messages, considering both known and unforeseen litigation. The policy should also address the destruction of e-mails after a specified time to protect the nature and confidentiality of the messages themselves. Addressing the retention issue in the e-mail policy would facilitate recovery, rebuilding and reuse.

QUESTION 101

In an organization where an IT security baseline has been defined, an IS auditor should FIRST ensure:

- A. implementation.

- B. compliance.
- C. documentation.
- D. sufficiency.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor should first evaluate the definition of the minimum baseline level by ensuring the sufficiency of controls. Documentation, implementation and compliance are further steps.

QUESTION 102

To ensure an organization is complying with privacy requirements, an IS auditor should FIRST review:

- A. the IT infrastructure.
- B. organizational policies, standards and procedures.
- C. legal and regulatory requirements.
- D. the adherence to organizational policies, standards and procedures.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

To ensure that the organization is complying with privacy issues, an IS auditor should address legal and regulatory requirements first. To comply with legal and regulatory requirements, organizations need to adopt the appropriate infrastructure. After understanding the legal and regulatory requirements, an IS auditor should evaluate organizational policies, standards and procedures to determine whether they adequately address the privacy requirements, and then review the adherence to these specific policies, standards and procedures.

QUESTION 103

A top-down approach to the development of operational policies will help ensure:

- A. that they are consistent across the organization.
- B. that they are implemented as a part of risk assessment.
- C. compliance with all policies.
- D. that they are reviewed periodically.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Deriving lower level policies from corporate policies (a top-down approach) aids in ensuring consistency across the organization and consistency with other policies. The bottom-up approach to the development of operational policies is derived as a result of risk assessment. A top-down approach of itself does not ensure compliance and development does not ensure that policies are reviewed.

QUESTION 104

Which of the following would MOST likely indicate that a customer data warehouse should remain in-house rather than be outsourced to an offshore operation?

- A. Time zone differences could impede communications between IT teams.
- B. Telecommunications cost could be much higher in the first year.
- C. Privacy laws could prevent cross-border flow of information.
- D. Software development may require more detailed specifications.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Privacy laws prohibiting the cross-border flow of personally identifiable information would make it impossible to locate a data warehouse containing customer information in another country. Time zone differences and higher telecommunications costs are more manageable. Software development typically requires more detailed specifications when dealing with offshore operations.

QUESTION 105

A retail outlet has introduced radio frequency identification (RFID) tags to create unique serial numbers for all products. Which of the following is the PRIMARY concern associated with this initiative?

- A. Issues of privacy
- B. Wavelength can be absorbed by the human body
- C. RFID tags may not be removable
- D. RFID eliminates line-of-sight reading

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The purchaser of an item will not necessarily be aware of the presence of the tag. If a tagged item is paid for by credit card, it would be possible to tie the unique ID of that item to the identity of the purchaser. Privacy violations are a significant concern because RFID can carry unique identifier numbers. If desired it would be possible for a firm to track individuals who purchase an item containing an RFID. Choices B and C are concerns of less importance. Choice D is not a concern.

QUESTION 106

When developing a security architecture, which of the following steps should be executed FIRST?

- A. Developing security procedures
- B. Defining a security policy
- C. Specifying an access control methodology

D. Defining roles and responsibilities

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Defining a security policy for information and related technology is the first step toward building a security architecture. A security policy communicates a coherent security standard to users, management and technical staff. Security policies will often set the stage in terms of what tools and procedures are needed for an organization. The other choices should be executed only after defining a security policy.

QUESTION 107

An IS auditor finds that, in accordance with IS policy, IDs of terminated users are deactivated within 90 days of termination. The IS auditor should:

- A. report that the control is operating effectively since deactivation happens within the time frame stated in the IS policy.
- B. verify that user access rights have been granted on a need-to-have basis.
- C. recommend changes to the IS policy to ensure deactivation of user IDs upon termination.
- D. recommend that activity logs of terminated users be reviewed on a regular basis.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Although a policy provides a reference for performing IS audit assignments, an IS auditor needs to review the adequacy and the appropriateness of the policy. If, in the opinion of the auditor, the time frame defined for deactivation is inappropriate, the auditor needs to communicate this to management and recommend changes to the policy. Though the deactivation happens as stated in the policy, it cannot be concluded that the control is effective. Best practice would require that the ID of a terminated user be deactivated immediately. Verifying that user access rights have been granted on a need-to-have basis is necessary when permissions are granted.

Recommending that activity logs of terminated users be reviewed on a regular basis is a good practice, but not as effective as deactivation upon termination.

QUESTION 108

An IS auditor is reviewing a project to implement a payment system between a parent bank and a subsidiary.

The IS auditor should FIRST verify that the:

- A. technical platforms between the two companies are interoperable.
- B. parent bank is authorized to serve as a service provider.
- C. security features are in place to segregate subsidiary trades.
- D. subsidiary can join as a co-owner of this payment system.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Even between parent and subsidiary companies, contractual agreement(s) should be in place to conduct shared services. This is particularly important in highly regulated organizations such as banking. Unless granted to serve as a service provider, it may not be legal for the bank to extend business to the subsidiary companies. Technical aspects should always be considered; however, this can be initiated after confirming that the parent bank can serve as a service provider. Security aspects are another important factor; however, this should be considered after confirming that the parent bank can serve as a service provider. The ownership of the payment system is not as important as the legal authorization to operate the system.

QUESTION 109

IT control objectives are useful to IS auditors, as they provide the basis for understanding the:

- A. desired result or purpose of implementing specific control procedures.
- B. best IT security control practices relevant to a specific entity.
- C. techniques for securing information.
- D. security policy.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IT control objective is defined as the statement of the desired result or purpose to be achieved by implementing control procedures in a particular IT activity.

They provide the actual objectives for implementing controls and may or may not be the best practices. Techniques are the means of achieving an objective, and a security policy is a subset of IT control objectives.

QUESTION 110

Which of the following provides the best evidence of the adequacy of a security awareness program?

- A. The number of stakeholders including employees trained at various levels
- B. Coverage of training at all locations across the enterprise
- C. The implementation of security devices from different vendors
- D. Periodic reviews and comparison with best practices

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The adequacy of security awareness content can best be assessed by determining whether it is periodically reviewed and compared to industry best practices.

Choices A, B and C provide metrics for measuring various aspects of a security awareness program, but do not help assess the content.

QUESTION 111

The PRIMARY objective of implementing corporate governance by an organization's management is to:

- A. provide strategic direction.
- B. control business operations.

- C. align IT with business.
- D. implement best practices.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Corporate governance is a set of management practices to provide strategic direction, thereby ensuring that goals are achievable, risks are properly addressed and organizational resources are properly utilized. Hence, the primary objective of corporate governance is to provide strategic direction. Based on the strategic direction, business operations are directed and controlled.

QUESTION 112

Which of the following should an IS auditor recommend to BEST enforce alignment of an IT project portfolio with strategic organizational priorities?

- A. Define a balanced scorecard (BSC) for measuring performance
- B. Consider user satisfaction in the key performance indicators (KPIs)
- C. Select projects according to business benefits and risks
- D. Modify the yearly process of defining the project portfolio

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Prioritization of projects on the basis of their expected benefit(s) to business, and the related risks, is the best measure for achieving alignment of the project portfolio to an organization's strategic priorities. Modifying the yearly process of the projects portfolio definition might improve the situation, but only if the portfolio definition process is currently not tied to the definition of corporate strategies; however, this is unlikely since the difficulties are in maintaining the alignment, and not in setting it up initially. Measures such as balanced scorecard (BSC) and key performance indicators (KPIs) are helpful, but they do not guarantee that the projects are aligned with business strategy.

QUESTION 113

An example of a direct benefit to be derived from a proposed IT-related business investment is:

- A. enhanced reputation.
- B. enhanced staff morale.
- C. the use of new technology.
- D. increased market penetration.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A comprehensive business case for any proposed IT-related business investment should have clearly defined business benefits to enable the expected return to be calculated. These benefits usually fall into two categories: direct and indirect, or soft. Direct benefits usually comprise the quantifiable financial benefits that the new system is expected to generate. The potential benefits of enhanced reputation and enhanced staff morale are difficult to quantify, but should be quantified to the extent possible. IT investments should not be made just for the sake of new technology but should be based on a quantifiable business need.

QUESTION 114

To assist an organization in planning for IT investments, an IS auditor should recommend the use of:

- A. project management tools.
- B. an object-oriented architecture.
- C. tactical planning.
- D. enterprise architecture (EA).

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Enterprise architecture (EA) involves documenting the organization's IT assets and processes in a structured manner to facilitate understanding, management and planning for IT investments. It involves both a current state and a representation of an optimized future state. In attempting to complete an EA, organizations can address the problem either from a technology perspective or a business process perspective. Project management does not consider IT investment aspects; it is a tool to aid in delivering projects. Object-oriented architecture is a software development methodology and does not assist in planning for IT investment, while tactical planning is relevant only after high-level IT investment decisions have been made.

QUESTION 115

A benefit of open system architecture is that it:

- A. facilitates interoperability.
- B. facilitates the integration of proprietary components.
- C. will be a basis for volume discounts from equipment vendors.
- D. allows for the achievement of more economies of scale for equipment.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Open systems are those for which suppliers provide components whose interfaces are defined by public standards, thus facilitating interoperability between systems made by different vendors. In contrast, closed system components are built to proprietary standards so that other suppliers' systems cannot or will not interface with existing systems.

QUESTION 116

In the context of effective information security governance, the primary objective of value delivery is to:

- A. optimize security investments in support of business objectives.

- B. implement a standard set of security practices.
- C. institute a standards-based solution.
- D. implement a continuous improvement culture.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

In the context of effective information security governance, value delivery is implemented to ensure optimization of security investments in support of business objectives. The tools and techniques for implementing value delivery include implementation of a standard set of security practices, institutionalization and commoditization of standards-based solutions, and implementation of a continuous improvement culture considering security as a process, not an event.

QUESTION 117

Which of the following BEST supports the prioritization of new IT projects?

- A. Internal control self-assessment (CSA)
- B. Information systems audit
- C. Investment portfolio analysis
- D. Business risk assessment

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is most desirable to conduct an investment portfolio analysis, which will present not only a clear focus on investment strategy, but will provide the rationale for terminating nonperforming IT projects. Internal control self-assessment (CSA) may highlight noncompliance to the current policy, but may not necessarily be the best source for driving the prioritization of IT projects. Like internal CSA, IS audits may provide only part of the picture for the prioritization of IT projects. Business risk analysis is part of the investment portfolio analysis but, by itself, is not the best method for prioritizing new IT projects.

QUESTION 118

After the merger of two organizations, multiple self-developed legacy applications from both companies are to be replaced by a new common platform. Which of the following would be the GREATEST risk?

- A. Project management and progress reporting is combined in a project management office which is driven by external consultants.
- B. The replacement effort consists of several independent projects without integrating the resource allocation in a portfolio management approach.
- C. The resources of each of the organizations are inefficiently allocated while they are being familiarized with the other company's legacy systems.
- D. The new platform will force the business areas of both organizations to change their work processes, which will result in extensive training needs.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The efforts should be consolidated to ensure alignment with the overall strategy of the post-merger organization. If resource allocation is not centralized, the separate projects are at risk of overestimating the availability of key knowledge resources for the in-house developed legacy applications. In post-merger integration programs, it is common to form project management offices to ensure standardized and comparable information levels in the planning and reporting structures, and to centralize dependencies of project deliverables or resources. The experience of external consultants can be valuable since project management practices do not require in-depth knowledge of the legacy systems. This can free up resources for functional tasks. It is a good idea to first get familiar with the old systems, to understand what needs to be done in a migration and to evaluate the implications of technical decisions. In most cases, mergers result in application changes and thus in training needs as organizations and processes change to leverage the intended synergy effects of the merger.

QUESTION 119

Which of the following is the MOST important function to be performed by IS management when a service has been outsourced?

- A. Ensuring that invoices are paid to the provider
- B. Participating in systems design with the provider
- C. Renegotiating the provider's fees
- D. Monitoring the outsourcing provider's performance

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

In an outsourcing environment, the company is dependent on the performance of the service provider. Therefore, it is critical the outsourcing provider's performance be monitored to ensure that services are delivered to the company as required. Payment of invoices is a finance function, which would be completed per contractual requirements. Participating in systems design is a byproduct of monitoring the outsourcing provider's performance, while renegotiating fees is usually a one-time activity.

QUESTION 120

Is it appropriate for an IS auditor from a company that is considering outsourcing its IS processing to request and review a copy of each vendor's business continuity plan?

- A. Yes, because an IS auditor will evaluate the adequacy of the service bureau's plan and assist their company in implementing a complementary plan.
- B. Yes, because based on the plan, an IS auditor will evaluate the financial stability of the service bureau and its ability to fulfill the contract.
- C. No, because the backup to be provided should be specified adequately in the contract.
- D. No, because the service bureau's business continuity plan is proprietary information.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary responsibility of an IS auditor is to assure that the company assets are being safeguarded. This is true even if the assets do not reside on the immediate premises. Reputable service bureaus will have a well-designed and tested business continuity plan.

QUESTION 121

An IS auditor reviewing an outsourcing contract of IT facilities would expect it to define the:

- A. hardware configuration.
- B. access control software.
- C. ownership of intellectual property.
- D. application development methodology.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Of the choices, the hardware and access control software is generally irrelevant as long as the functionality, availability and security can be affected, which are specific contractual obligations. Similarly, the development methodology should be of no real concern. The contract must, however, specify who owns the intellectual property (i.e., information being processed, application programs). Ownership of intellectual property will have a significant cost and is a key aspect to be defined in an outsourcing contract.

QUESTION 122

When performing a review of the structure of an electronic funds transfer (EFT) system, an IS auditor observes that the technological infrastructure is based on a centralized processing scheme that has been outsourced to a provider in another country. Based on this information, which of the following conclusions should be the main concern of the IS auditor?

- A. There could be a question regarding the legal jurisdiction.
- B. Having a provider abroad will cause excessive costs in future audits.
- C. The auditing process will be difficult because of the distance.
- D. There could be different auditing norms.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In the funds transfer process, when the processing scheme is centralized in a different country, there could be legal issues of jurisdiction that might affect the right to perform a review in the other country. The other choices, though possible, are not as relevant as the issue of legal jurisdiction.

QUESTION 123

An IS auditor should expect which of the following items to be included in the request for proposal (RFP) when IS is procuring services from an independent service provider (ISP)?

- A. References from other customers
- B. Service level agreement (SLA) template
- C. Maintenance agreement
- D. Conversion plan

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor should look for an independent verification that the ISP can perform the tasks being contracted for. References from other customers would provide an independent, external review and verification of procedures and processes the ISP follows-issues which would be of concern to an IS auditor. Checking references is a means of obtaining an independent verification that the vendor can perform the services it says it can. A maintenance agreement relates more to equipment than to services, and a conversion plan, while important, is less important than verification that the ISP can provide the services they propose.

QUESTION 124

To minimize costs and improve service levels an outsourcer should seek which of the following contract clauses?

- A. O/S and hardware refresh frequencies
- B. Gain-sharing performance bonuses
- C. Penalties for noncompliance
- D. Charges tied to variable cost metrics

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Because the outsourcer will share a percentage of the achieved savings, gain-sharing performance bonuses provide a financial incentive to go above and beyond the stated terms of the contract and can lead to cost savings for the client. Refresh frequencies and penalties for noncompliance would only encourage the outsourcer to meet minimum requirements. Similarly, tying charges to variable cost metrics would not encourage the outsourcer to seek additional efficiencies that might benefit the client.

QUESTION 125

When an organization is outsourcing their information security function, which of the following should be kept in the organization?

- A. Accountability for the corporate security policy
- B. Defining the corporate security policy
- C. Implementing the corporate security policy
- D. Defining security procedures and guidelines

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Accountability cannot be transferred to external parties. Choices B, C and D can be performed by outside entities as long as accountability remains within the organization.

QUESTION 126

An IS auditor has been assigned to review IT structures and activities recently outsourced to various providers. Which of the following should the IS auditor determine FIRST?

- A. That an audit clause is present in all contracts
- B. That the SLA of each contract is substantiated by appropriate KPIs
- C. That the contractual warranties of the providers support the business needs of the organization
- D. That at contract termination, support is guaranteed by each outsourcer for new outsourcers

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The complexity of IT structures matched by the complexity and interplay of responsibilities and warranties may affect or void the effectiveness of those warranties and the reasonable certainty that the business needs will be met. All other choices are important, but not as potentially dangerous as the interplay of the diverse and critical areas of the contractual responsibilities of the outsourcers.

QUESTION 127

With respect to the outsourcing of IT services, which of the following conditions should be of GREATEST concern to an IS auditor?

- A. Outsourced activities are core and provide a differentiated advantage to the organization.
- B. Periodic renegotiation is specified in the outsourcing contract.
- C. The outsourcing contract fails to cover every action required by the arrangement.
- D. Similar activities are outsourced to more than one vendor.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An organization's core activities generally should not be outsourced, because they are what the organization does best; an IS auditor observing that should be concerned. An IS auditor should not be concerned about the other conditions because specification of periodic renegotiation in the outsourcing contract is a best practice. Outsourcing contracts cannot be expected to cover every action and detail expected of the parties involved, while multisourcing is an acceptable way to reduce risk.

QUESTION 128

While conducting an audit of a service provider, an IS auditor observes that the service provider has outsourced a part of the work to another provider. Since the work involves confidential information, the IS auditor's PRIMARY concern should be that the:

- A. requirement for protecting confidentiality of information could be compromised.
- B. contract may be terminated because prior permission from the outsourcer was not obtained.
- C. other service provider to whom work has been outsourced is not subject to audit.
- D. outsourcer will approach the other service provider directly for further work.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Many countries have enacted regulations to protect the confidentiality of information maintained in their countries and/or exchanged with other countries. Where a service provider outsources part of its services to

another service provider, there is a potential risk that the confidentiality of the information will be compromised. Choices B and C could be concerns but are not related to ensuring the confidentiality of information. There is no reason why an IS auditor should be concerned with choice D.

QUESTION 129

Which of the following is the BEST information source for management to use as an aid in the identification of assets that are subject to laws and regulations?

- A. Security incident summaries
- B. Vendor best practices
- C. CERT coordination center
- D. Significant contracts

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Contractual requirements are one of the sources that should be consulted to identify the requirements for the management of information assets. Vendor best practices provides a basis for evaluating how competitive an enterprise is, while security incident summaries are a source for assessing the vulnerabilities associated with the IT infrastructure. CERT (www.cert.org) is an information source for assessing vulnerabilities within the IT infrastructure.

QUESTION 130

An organization has outsourced its help desk activities. An IS auditor's GREATEST concern when reviewing the contract and associated service level agreement (SLA) between the organization and vendor should be the provisions for:

- A. documentation of staff background checks.
- B. independent audit reports or full audit access.
- C. reporting the year-to-year incremental cost reductions.
- D. reporting staff turnover, development or training.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When the functions of an IS department are outsourced, an IS auditor should ensure that a provision is made for independent audit reports that cover all essential areas, or that the outsourcer has full audit access. Although it is necessary to document the fact that background checks are performed, this is not as important as provisions for audits. Financial measures such as year-to-year incremental cost reductions are desirable to have in a service level agreement (SLA); however, cost

reductions are not as important as the availability of independent audit reports or full audit access. An SLA might include human relationship measures such as resource planning, staff turnover, development or training, but this is not as important as the requirements for independent reports or full audit access by the outsourcing organization.

QUESTION 131

Which of the following is the MOST important IS audit consideration when an organization outsources a customer credit review system to a third-party service provider? The provider:

- A. meets or exceeds industry security standards.
- B. agrees to be subject to external security reviews.
- C. has a good market reputation for service and experience.
- D. complies with security policies of the organization.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is critical that an independent security review of an outsourcing vendor be obtained because customer credit information will be kept there. Compliance with security standards or organization policies is important, but there is no way to verify or prove that that is the case without an independent review. Though long experience in business and good reputation is an important factor to assess service quality, the business cannot outsource to a provider whose security control is weak.

QUESTION 132

The risks associated with electronic evidence gathering would MOST likely be reduced by an e- mail:

- A. destruction policy.
- B. security policy.
- C. archive policy.
- D. audit policy.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

With a policy of well-archived e-mail records, access to or retrieval of specific e-mail records is possible without disclosing other confidential e-mail records. Security and/or audit policies would not address the efficiency of record retrieval, and destroying e-mails may be an illegal act.

QUESTION 133

The output of the risk management process is an input for making:

- A. business plans.
- B. audit charters.
- C. security policy decisions.
- D. software design decisions.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The risk management process is about making specific, security-related decisions, such as the level of acceptable risk. Choices A, B and D are not ultimate goals of the risk management process.

QUESTION 134

An IS auditor was hired to review e-business security. The IS auditor's first task was to examine each existing e-business application looking for vulnerabilities. What would be the next task?

- A. Report the risks to the CIO and CEO immediately
- B. Examine e-business application in development
- C. Identify threats and likelihood of occurrence
- D. Check the budget available for risk management

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor must identify the assets, look for vulnerabilities, and then identify the threats and the likelihood of occurrence. Choices A, B and D should be discussed with the CIO, and a report should be delivered to the CEO. The report should include the findings along with priorities and costs.

QUESTION 135

Which of the following is a mechanism for mitigating risks?

- A. Security and control practices
- B. Property and liability insurance
- C. Audit and certification
- D. Contracts and service level agreements (SLAs)

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Risks are mitigated by implementing appropriate security and control practices. Insurance is a mechanism for transferring risk. Audit and certification are mechanisms of risk assurance, while contracts and SLAs are mechanisms of risk allocation.

QUESTION 136

When developing a risk management program, what is the FIRST activity to be performed?

- A. Threat assessment
- B. Classification of data
- C. Inventory of assets
- D. Criticality analysis

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Identification of the assets to be protected is the first step in the development of a risk management program. A listing of the threats that can affect the performance of these assets and criticality analysis are later steps in the process. Data classification is required for defining access controls and in criticality analysis.

QUESTION 137

A team conducting a risk analysis is having difficulty projecting the financial losses that could result from a risk. To evaluate the potential losses, the team should:

- A. compute the amortization of the related assets.
- B. calculate a return on investment (ROI).
- C. apply a qualitative approach.
- D. spend the time needed to define exactly the loss amount.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The common practice, when it is difficult to calculate the financial losses, is to take a qualitative approach, in which the manager affected by the risk defines the financial loss in terms of a weighted factor {e.g., one is a very low impact to the business and five is a very high impact}. An ROI is computed when there is predictable savings or revenues that can be compared to the investment needed to realize the revenues. Amortization is used in a profit and loss statement, not in computing potential losses. Spending the time needed to define exactly the total amount is normally a wrong approach. If it has been difficult to estimate potential losses (e.g., losses derived from erosion of public image due to a hack attack), that situation is not likely to change, and at the end of the day, the result will be a not well-supported evaluation.

QUESTION 138

Which of the following provides the MOST helpful information to determine how much data an organization can afford to lose when a critical system failure occurs?

- A. Industry data loss statistics
- B. Risk assessment results
- C. Recovery point objective (RPO)
- D. Recovery time objective (RTO)

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 139

In an online application, which of the following would provide the MOST information about the transaction audit trail?

- A. File layouts
- B. System/process flowchart
- C. Source code documentation
- D. Data architecture

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 140

Which of the following firewall technologies involves examining the header of every packet of data traveling between the Internet and the corporate network without examining the previous packets?

- A. Proxy servers
- B. Bastion host
- C. Stateful filtering
- D. Stateless filtering

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 141

A system administrator recently informed the IS auditor about the occurrence of several unsuccessful intrusion attempts from outside the organization. Which of the following is MOST effective in detecting such an intrusion?

- A. Installing biometrics-based authentication
- B. Configuring the router as a firewall
- C. Periodically reviewing log files
- D. Using smart cards with one-time passwords

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 142

Which of the following are used in a firewall to protect the entity's internal resources?

- A. Internet Protocol (IP) address restrictions
- B. Remote access servers
- C. Secure Sockets Layers (SSLs)
- D. Fail-over services

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 143

A company has located its computer center on a moderate earthquake fault. Which of the following is the MOST important consideration in establishing a contingency plan and an alternate processing site?

- A. The alternative site does not reside on the same fault no matter how far the distance apart.
- B. The contingency plan for high priority applications does not involve a shared cold site.
- C. The alternative site is a hot site with equipment ready to resume processing immediately.
- D. The contingency plan provides for backup tapes to be taken to the alternative site.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 144

Which of the following is the BEST way to address potential data privacy concerns associated with inadvertent disclosure of machine identifier information contained within security logs?

- A. Only collect logs from servers classified as business critical.
- B. Limit the use of logs to only those purposes for which they were collected.
- C. Limit log collection to only periods of increased security activity.
- D. Restrict the transfer of log files from host machine to online storage.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 145

The PRIMARY benefit to using a dry-pipe fire-suppression system rather than a wet-pipe system is that a dry- pipe system:

- A. has a decreased risk of leakage.
- B. is more effective at suppressing flames.
- C. allows more time to abort release of the suppressant.
- D. disperses dry chemical suppressants exclusively.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 146

On a public-key cryptosystem when there is no previous knowledge between parties, which of the following will BEST help to prevent one person from using a fictitious key to impersonate someone else?

- A. Encrypt the message containing the sender's public key, using a private-key cryptosystem.
- B. Send a certificate that can be verified by a certification authority with the public key.
- C. Encrypt the message containing the sender's public key; using the recipient's public key.
- D. Send the public key to the recipient prior to establishing the connection.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 147

Which of the following should be the PRIMARY basis for how digital evidence is handled during a forensics investigation?

- A. Industry best practices
- B. Regulatory requirements
- C. Organizational risk culture
- D. Established business practices

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 148

A database administrator should be prevented from:

- A. using an emergency user ID.
- B. accessing sensitive information.
- C. having end user responsibilities.
- D. having access to production files.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 149

Which of the following security risks can be reduced by a properly configured network firewall?

- A. Insider attacks
- B. SQL injection attacks
- C. Denial of service (DoS) attacks
- D. Phishing attacks

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 150

Which of the following does a lack of adequate security controls represent?

- A. Threat
- B. Asset
- C. Impact
- D. Vulnerability

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets
The lack of adequate security controls represents a vulnerability, exposing sensitive information and data to the risk of malicious damage, attack or unauthorized access by hackers. This could result in a loss of sensitive information and lead to the loss of goodwill for the organization. A succinct definition of risk is provided by the Guidelines for the Management of IT Security published by the International Organization for Standardization (ISO), which defines risk as the 'potential that a given threat will exploit the vulnerability of an asset or group of assets to cause loss or damage to the assets.' The various elements of the definition are vulnerability, threat, asset and impact. Lack of adequate security functionality in this context is a vulnerability.

QUESTION 151

Assessing IT risks is BEST achieved by:

- A. evaluating threats associated with existing IT assets and IT projects.
- B. using the firm's past actual loss experience to determine current exposure.
- C. reviewing published loss statistics from comparable organizations.
- D. reviewing IT control weaknesses identified in audit reports.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets
To assess IT risks, threats and vulnerabilities need to be evaluated using qualitative or quantitative risk assessment approaches. Choices B, C and D are potentially useful inputs to the risk assessment process, but by themselves are not sufficient. Basing an assessment on past losses will not adequately reflect inevitable changes to the firm's IT assets, projects, controls and strategic environment. There are also likely to be problems with the scope and quality of the loss data available to be assessed. Comparable organizations will have differences in their IT assets, control environment and strategic circumstances. Therefore, their loss experience cannot be used to directly assess organizational IT risk. Control weaknesses identified during audits will be relevant in assessing threat exposure and further analysis may be needed to assess threat probability. Depending on the scope of the audit coverage, it is possible that not all of the critical IT assets and projects will have recently been audited, and there may not be a sufficient assessment of strategic IT risks.

QUESTION 152

Which of the following terms refers to systems designed to detect and prevent the unauthorized transmission of information from the computer systems of an organization to outsiders?

- A. ILD&P
- B. ICT&P
- C. ILP&C
- D. ILR&D
- E. None of the choices.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

Information Leakage Detection and Prevention (ILD&P) is a computer security term referring to systems designed to detect and prevent the unauthorized transmission of information from the computer systems of an organization to outsiders. Network ILD&P are gateway-based systems installed on the organization's internet network connection and analyze network traffic to search for unauthorized information transmissions. Host Based ILD&P systems run on end-user workstations to monitor and control access to physical devices and access information before it has been encrypted.

QUESTION 153

To address the risk of operations staff's failure to perform the daily backup, management requires that the systems administrator sign off on the daily backup. This is an example of risk:

- A. avoidance
- B. transference
- C. mitigation
- D. acceptance

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Mitigation is the strategy that provides for the definition and implementation of controls to address the risk described. Avoidance is a strategy that provides for not implementing certain activities or processes that would incur risk. Transference is the strategy that provides for sharing risk with partners or taking insurance coverage. Acceptance is a strategy that provides for formal acknowledgement of the existence of a risk and the monitoring of that risk.

QUESTION 154

A poor choice of passwords and transmission over unprotected communications lines are examples of:

- A. vulnerabilities.
- B. threats.
- C. probabilities.
- D. impacts.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Vulnerabilities represent characteristics of information resources that may be exploited by a threat. Threats are circumstances or events with the potential to cause harm to information resources. Probabilities represent the likelihood of the occurrence of a threat, while impacts represent the outcome or result of a threat exploiting a vulnerability.

QUESTION 155

An IS auditor reviewing the risk assessment process of an organization should FIRST:

- A. identify the reasonable threats to the information assets.
- B. analyze the technical and organizational vulnerabilities.
- C. identify and rank the information assets.
- D. evaluate the effect of a potential security breach.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Identification and ranking of information assets-e.g., data criticality, locations of assets-will set the tone or scope of how to assess risk in relation to the organizational value of the asset. Second, the threats facing each of the organization's assets should be analyzed according to their value to the organization. Third,

weaknesses should be identified so that controls can be evaluated to determine if they mitigate the weaknesses. Fourth, analyze how these weaknesses, in absence of given controls, would impact the organization information assets.

QUESTION 156

An IS auditor is reviewing an IT security risk management program. Measures of security risk should:

- A. address all of the network risks.
- B. be tracked over time against the IT strategic plan.
- C. take into account the entire IT environment.
- D. result in the identification of vulnerability tolerances.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When assessing IT security risk, it is important to take into account the entire IT environment. Measures of security risk should focus on those areas with the highest criticality so as to achieve maximum risk reduction at the lowest possible cost. IT strategic plans are not granular enough to provide appropriate measures. Objective metrics must be tracked over time against measurable goals, thus the management of risk is enhanced by comparing today's results against last week, last month, last quarter. Risk measures will profile assets on a network to objectively measure vulnerability risk. They do not identify tolerances.

QUESTION 157

Which of the following should be considered FIRST when implementing a risk management program?

- A. An understanding of the organization's threat, vulnerability and risk profile
- B. An understanding of the risk exposures and the potential consequences of compromise
- C. A determination of risk management priorities based on potential consequences
- D. A risk mitigation strategy sufficient to keep risk consequences at an acceptable level

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Implementing risk management, as one of the outcomes of effective information security governance, would require a collective understanding of the organization's threat, vulnerability and risk profile as a first step. Based on this, an understanding of risk exposure and potential consequences of compromise could be determined. Risk management priorities based on potential consequences could then be developed. This would provide a basis for the formulation of strategies for risk mitigation sufficient to keep the consequences from risk at an acceptable level.

QUESTION 158

As a driver of IT governance, transparency of IT's cost, value and risks is primarily achieved through:

- A. performance measurement.
- B. strategic alignment.
- C. value delivery.
- D. resource management.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Performance measurement includes setting and monitoring measurable objectives of what the IT processes need to deliver (process outcome) and how they deliver it (process capability and performance). Strategic alignment primarily focuses on ensuring linkage of business and IT plans. Value delivery is about executing the value proposition throughout the delivery cycle. Resource management is about the optimal investment in and proper management of critical IT resources. Transparency is primarily achieved through performance measurement as it provides information to the stakeholders on how well the enterprise is performing when compared to objectives.

QUESTION 159

Which of the following should be the MOST important consideration when deciding areas of priority for IT governance implementation?

- A. Process maturity
- B. Performance indicators
- C. Business risk
- D. Assurance reports

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Priority should be given to those areas which represent a known risk to the enterprise's operations. The level of process maturity, process performance and audit reports will feed into the decision making process. Those areas that represent real risk to the business should be given priority.

QUESTION 160

The PRIMARY benefit of implementing a security program as part of a security governance framework is the:

- A. alignment of the IT activities with IS audit recommendations.
- B. enforcement of the management of security risks.
- C. implementation of the chief information security officer's (CISO) recommendations.
- D. reduction of the cost for IT security.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The major benefit of implementing a security program is management's assessment of risk and its mitigation to an appropriate level of risk, and the monitoring of the remaining residual risks. Recommendations, visions and objectives of the auditor and the chief information security officer (CISO) are usually included within a security program, but they would not be the major benefit.

The cost of IT security may or may not be reduced.

QUESTION 161

An IS auditor who is reviewing incident reports discovers that, in one instance, an important document left on an employee's desk was removed and put in the garbage by the outsourced cleaning staff. Which of the following should the IS auditor recommend to management?

- A. Stricter controls should be implemented by both the organization and the cleaning agency.
- B. No action is required since such incidents have not occurred in the past.
- C. A clear desk policy should be implemented and strictly enforced in the organization.
- D. A sound backup policy for all important office documents should be implemented.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

An employee leaving an important document on a desk and the cleaning staff removing it may result in a serious impact on the business. Therefore, the IS auditor should recommend that strict controls be implemented by both the organization and the outsourced cleaning agency. That such incidents have not occurred in the past does not reduce the seriousness of their impact. Implementing and monitoring a clear desk policy addresses only one part of the issue. Appropriate confidentiality agreements with the cleaning agency, along with ensuring that the cleaning staff has been educated on the dos and don'ts of the cleaning process, are also controls that should be implemented. The risk here is not a loss of data, but leakage of data to unauthorized sources. A backup policy does not address the issue of unauthorized leakage of information.

QUESTION 162

During an audit, an IS auditor notices that the IT department of a medium-sized organization has no separate risk management function, and the organization's operational risk documentation only contains a few broadly described IT risks. What is the MOST appropriate recommendation in this situation?

- A. Create an IT risk management department and establish an IT risk framework with the aid of external risk management experts.
- B. Use common industry standard aids to divide the existing risk documentation into several individual risks which will be easier to handle.
- C. No recommendation is necessary since the current approach is appropriate for a medium-sized organization.
- D. Establish regular IT risk management meetings to identify and assess risks, and create a mitigation plan as input to the organization's risk management.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Establishing regular meetings is the best way to identify and assess risks in a medium-sized organization, to address responsibilities to the respective management and to keep the risk list and mitigation plans up to date. A medium-sized organization would normally not have a separate IT risk management department. Moreover, the risks are usually manageable enough so that external help would not be needed. While common risks may be covered by common industry standards, they cannot address the specific situation of an organization. Individual risks will not be discovered without a detailed assessment from within the organization. Splitting the one risk position into several is not sufficient.

QUESTION 163

The IT balanced scorecard is a business governance tool intended to monitor IT performance evaluation indicators other than:

- A. financial results.
- B. customer satisfaction.
- C. internal process efficiency.
- D. innovation capacity.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Financial results have traditionally been the sole overall performance metric. The IT balanced scorecard (BSC) is an IT business governance tool aimed at monitoring IT performance evaluation indicators other than financial results. The IT BSC considers other key success factors, such as customer satisfaction, innovation capacity and processing.

QUESTION 164

Before implementing an IT balanced scorecard, an organization must:

- A. deliver effective and efficient services.
- B. define key performance indicators.
- C. provide business value to IT projects.
- D. control IT expenses.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A definition of key performance indicators is required before implementing an IT balanced scorecard. Choices A, C and D are objectives.

QUESTION 165

Which of the following is the PRIMARY objective of an IT performance measurement process?

- A. Minimize errors
- B. Gather performance data
- C. Establish performance baselines
- D. Optimize performance

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IT performance measurement process can be used to optimize performance, measure and manage products/services, assure accountability and make budget decisions. Minimizing errors is an aspect of performance, but not the primary objective of performance management. Gathering performance data is a phase of IT measurement process and would be used to evaluate the performance against previously established performance baselines.

QUESTION 166

When auditing the proposed acquisition of a new computer system, an IS auditor should FIRST establish that:

- A. a clear business case has been approved by management.
- B. corporate security standards will be met.
- C. users will be involved in the implementation plan.
- D. the new system will meet all required user functionality.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The first concern of an IS auditor should be to establish that the proposal meets the needs of the business, and this should be established by a clear business case. Although compliance with security standards is essential, as is meeting the needs of the users and having users involved in the implementation process, it is too early in the procurement process for these to be an IS auditor's first concern.

QUESTION 167

Documentation of a business case used in an IT development project should be retained until:

- A. the end of the system's life cycle.
- B. the project is approved.
- C. user acceptance of the system.
- D. the system is in production.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A business case can and should be used throughout the life cycle of the product. It serves as an anchor for new (management) personnel, helps to maintain focus and provides valuable information on estimates vs. actuals. Questions like, 'why do we do that', 'What was the original intent' and 'how did we perform against the plan' can be answered, and lessons for developing future business cases can be learned. During the development phase of a project one should always validate the business case, as it is a good management instrument. After finishing a project and entering production, the business case and all the completed research are valuable sources of information that should be kept for further reference

QUESTION 168

Which of the following risks could result from inadequate software baselining?

- A. Scope creep
- B. Sign-off delays
- C. Software integrity violations
- D. inadequate controls

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A software baseline is the cut-off point in the design and development of a system beyond which additional requirements or modifications to the design do not or cannot occur without undergoing formal strict procedures for approval based on a business cost-benefit analysis. Failure to adequately manage the requirements of a system through baselining can result in a number of risks. Foremost among these risks is scope creep, the process through which requirements change during development. Choices, C and D may not always result, but choice A is inevitable.

QUESTION 169

The most common reason for the failure of information systems to meet the needs of users is that:

- A. user needs are constantly changing.
- B. the growth of user requirements was forecast inaccurately.
- C. the hardware system limits the number of concurrent users.
- D. user participation in defining the system's requirements was inadequate.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Lack of adequate user involvement, especially in the system's requirements phase, will usually result in a system that does not fully or adequately address the needs of the user. Only users can define what their needs are, and therefore what the system should accomplish.

QUESTION 170

Many IT projects experience problems because the development time and/or resource requirements are underestimated. Which of the following techniques would provide the GREATEST assistance in developing an estimate of project duration?

- A. Function point analysis
- B. PERT chart
- C. Rapid application development
- D. Object-oriented system development

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A PERT chart will help determine project duration once all the activities and the work involved with those activities are known. Function point analysis is a technique for determining the size of a development task based on the number of function points. Function points are factors such as inputs, outputs, inquiries, logical internal files, etc. While this will help determine the size of individual activities, it will not assist in determining project duration since there are many overlapping tasks. Rapid application development is a methodology that enables organizations to develop strategically important systems faster while reducing development costs and maintaining quality, while object-oriented system development is the process of solution specification and modeling.

QUESTION 171

The reason for establishing a stop or freezing point on the design of a new system is to:

- A. prevent further changes to a project in process.
- B. indicate the point at which the design is to be completed.
- C. require that changes after that point be evaluated for cost-effectiveness.
- D. provide the project management team with more control over the project design.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Projects often have a tendency to expand, especially during the requirements definition phase. This expansion

often grows to a point where the originally anticipated cost-benefits are diminished because the cost of the project has increased. When this occurs, it is recommended that the project be stopped or frozen to allow a review of all of the cost- benefits and the payback period.

QUESTION 172

Change control for business application systems being developed using prototyping could be complicated by the:

- A. iterative nature of prototyping.
- B. rapid pace of modifications in requirements and design.
- C. emphasis on reports and screens.
- D. lack of integrated tools.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Changes in requirements and design happen so quickly that they are seldom documented or approved. Choices A, C and D are characteristics of prototyping, but they do not have an adverse effect on change control.

QUESTION 173

An IS auditor finds that a system under development has 12 linked modules and each item of data can carry up to 10 definable attribute fields. The system handles several million transactions a year. Which of these techniques could an IS auditor use to estimate the size of the development effort?

- A. Program evaluation review technique (PERT)
- B. Counting source lines of code (SLOC)
- C. Function point analysis
- D. White box testing

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Function point analysis is an indirect method of measuring the size of an application by considering the number and complexity of its inputs, outputs and files. It is useful for evaluating complex applications. PERT is a project management technique that helps with both planning and control. SLOC gives a direct measure of program size, but does not allow for the complexity that may be caused by having multiple, linked modules and a variety of inputs and outputs. White box testing involves a detailed review of the behavior of program code, and is a quality assurance technique suited to simpler applications during the design and build stage of development.

QUESTION 174

When planning to add personnel to tasks imposing time constraints on the duration of a project, which of the following should be revalidated FIRST?

- A. The project budget
- B. The critical path for the project
- C. The length of the remaining tasks
- D. The personnel assigned to other tasks

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Since adding resources may change the route of the critical path, the critical path must be reevaluated to ensure that additional resources will in fact shorten the project duration. Given that there may be slack time available on some of the other tasks not on the critical path, factors such as the project budget, the length of other tasks and the personnel assigned to them may or may not be affected.

QUESTION 175

Which of the following is a characteristic of timebox management?

- A. Not suitable for prototyping or rapid application development (RAD)
- B. Eliminates the need for a quality process
- C. Prevents cost overruns and delivery delays
- D. Separates system and user acceptance testing

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Timebox management, by its nature, sets specific time and cost boundaries. It is very suitable for prototyping and RAD, and integrates system and user acceptance testing, but does not eliminate the need for a quality process.

QUESTION 176

Which of the following should an IS auditor review to gain an understanding of the effectiveness of controls over the management of multiple projects?

- A. Project database
- B. Policy documents
- C. Project portfolio database
- D. Program organization

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A project portfolio database is the basis for project portfolio management. It includes project data, such as owner, schedules, objectives, project type, status and cost. Project portfolio management requires specific project portfolio reports. A project database may contain the above for one specific project and updates to various parameters pertaining to the current status of that single project. Policy documents on project management set direction for the design, development, implementation and monitoring of the project. Program organization is the team required (steering committee, quality assurance, systems personnel, analyst, programmer, hardware support, etc.) to meet the delivery objective of the project.

QUESTION 177

To minimize the cost of a software project, quality management techniques should be applied:

- A. as close to their writing (i.e., point of origination) as possible.
- B. primarily at project start-up to ensure that the project is established in accordance with organizational governance standards.
- C. continuously throughout the project with an emphasis on finding and fixing defects primarily during testing to maximize the defect detection rate.
- D. mainly at project close-down to capture lessons learned that can be applied to future projects.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

While it is important to properly establish a software development project, quality management should be effectively practiced throughout the project. The major source of unexpected costs on most software projects is rework. The general rule is that the earlier in the development life cycle that a defect occurs, and the longer it takes to find and fix that defect, the more effort will be needed to correct it. A well-written quality management plan is a good start, but it must also be actively applied. Simply relying on testing to identify defects is a relatively costly and less effective way of achieving software quality. For example, an error in requirements discovered in the testing phase can result in scrapping significant amounts of work. Capturing lessons learned will be too late for the current project. Additionally, applying quality management techniques throughout a project is likely to yield its own insights into the causes of quality problems and assist in staff development.

QUESTION 178

When identifying an earlier project completion time, which is to be obtained by paying a premium for early completion, the activities that should be selected are those:

- A. whose sum of activity time is the shortest.
- B. that have zero slack time.
- C. that give the longest possible completion time.
- D. whose sum of slack time is the shortest.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A critical path's activity time is longer than that for any other path through the network. This path is important because if everything goes as scheduled, its length gives the shortest possible completion time for the overall project. Activities on the critical path become candidates for crashing, i.e., for reduction in their time by payment of a premium for early completion. Activities on the critical path have zero slack time and conversely, activities with zero slack time are on a critical path. By successively relaxing activities on a critical path, a curve showing total project costs vs. time can be obtained.

QUESTION 179

At the completion of a system development project, a post project review should include which of the following?

- A. Assessing risks that may lead to downtime after the production release
- B. Identifying lessons learned that may be applicable to future projects
- C. Verifying the controls in the delivered system are working
- D. Ensuring that test data are deleted

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A project team has something to learn from each and every project. As risk assessment is a key issue for project management, it is important for the organization to accumulate lessons learned and integrate them into future projects. An assessment of potential downtime should be made with the operations group and other specialists before implementing a system. Verifying that controls are working should be covered during the acceptance test phase and possibly, again, in the post implementation review. Test data should be retained for future regression testing.

QUESTION 180

An IS auditor has been asked to participate in project initiation meetings for a critical project. The IS auditor's MAIN concern should be that the:

- A. complexity and risks associated with the project have been analyzed.
- B. resources needed throughout the project have been determined.
- C. project deliverables have been identified.
- D. a contract for external parties involved in the project has been completed.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Understanding complexity and risk, and actively managing these throughout a project are critical to a successful outcome. The other choices, while important during the course of the project, cannot be fully determined at the time the project is initiated, and are often contingent upon the risk and complexity of the project.

QUESTION 181

An IS auditor invited to a development project meeting notes that no project risks have been documented. When the IS auditor raises this issue, the project manager responds that it is too early to identify risks and that, if risks do start impacting the project, a risk manager will be hired. The appropriate response of the IS auditor would be to:

- A. stress the importance of spending time at this point in the project to consider and document risks, and to develop contingency plans.
- B. accept the project manager's position as the project manager is accountable for the outcome of the project.
- C. offer to work with the risk manager when one is appointed.
- D. inform the project manager that the IS auditor will conduct a review of the risks at the completion of the requirements definition phase of the project.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Explanation: the majority of project risks can typically be identified before a project begins, allowing mitigation/ avoidance plans to be put in place to deal with the risks. A project should have a clear link back to corporate strategy and tactical plans to support this strategy. The process of setting corporate strategy, setting objectives and developing tactical plans should include the consideration of risks. Appointing a risk manager is a good practice but waiting until the project has been impacted by risks is misguided. Risk management needs to be forward looking; allowing risks to evolve into issues that adversely impact the project represents a failure of risk management. With or without a risk manager, persons within and outside of the project team need to be consulted and encouraged to comment when they believe new risks have emerged or risk priorities have changed. The IS auditor has an obligation to the project sponsor and the organization to advise on appropriate project management practices. Waiting for the possible appointment of a risk manager represents an

unnecessary and dangerous delay to implementing risk management.

QUESTION 182

While evaluating software development practices in an organization, an IS auditor notes that the quality assurance (QA) function reports to project management. The MOST important concern for an IS auditor is the:

- A. effectiveness of the QA function because it should interact between project management and user management
- B. efficiency of the QA function because it should interact with the project implementation team.
- C. effectiveness of the project manager because the project manager should interact with the QA function.
- D. efficiency of the project manager because the QA function will need to communicate with the project implementation team.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

To be effective the quality assurance (QA) function should be independent of project management. The QA function should never interact with the project implementation team since this can impact effectiveness. The project manager does not interact with the QA function, which should not impact the effectiveness of the project manager. The QA function does not interact with the project implementation team, which should not impact the efficiency of the project manager.

QUESTION 183

When reviewing a project where quality is a major concern, an IS auditor should use the project management triangle to explain that:

- A. increases in quality can be achieved, even if resource allocation is decreased.
- B. increases in quality are only achieved if resource allocation is increased.
- C. decreases in delivery time can be achieved, even if resource allocation is decreased.
- D. decreases in delivery time can only be achieved if quality is decreased.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The three primary dimensions of a project are determined by the deliverables, the allocated resources and the delivery time. The area of the project management triangle, comprised of these three dimensions, is fixed. Depending on the degree of freedom, changes in one dimension might be compensated by changing either one or both remaining dimensions. Thus, if resource allocation is decreased an increase in quality can be achieved, if a delay in the delivery time of the project will be accepted. The area of the triangle always remains constant.

QUESTION 184

An IS auditor is assigned to audit a software development project which is more than 80 percent complete, but has already overrun time by 10 percent and costs by 25 percent. Which of the following actions should the IS auditor take?

- A. Report that the organization does not have effective project management.
- B. Recommend the project manager be changed.
- C. Review the IT governance structure.
- D. Review the conduct of the project and the business case.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Before making any recommendations, an IS auditor needs to understand the project and the factors that have contributed to making the project over budget and over schedule. The organization may have effective project management practices and sound IT governance and still be behind schedule or over budget. There is no indication that the project manager should be changed without looking into the reasons for the overrun.

QUESTION 185

Which of the following should an IS auditor review to understand project progress in terms of time, budget and deliverables for early detection of possible overruns and for projecting estimates at completion (EACs)?

- A. Function point analysis
- B. Earned value analysis
- C. Cost budget
- D. Program Evaluation and Review Technique

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Earned value analysis (EVA) is an industry standard method for measuring a project's progress at any given point in time, forecasting its completion date and final cost, and analyzing variances in the schedule and budget as the project proceeds. It compares the planned amount of work with what has actually been completed, to determine if the cost, schedule and work accomplished are progressing in accordance with the plan. EVA works most effectively if a well-formed work breakdown structure exists. Function point analysis (FPA) is an indirect measure of software size and complexity and, therefore, does not address the elements of time and budget. Cost budgets do not address time. PERT aids in time and deliverables management, but lacks projections for estimates at completion (EACs) and overall financial management.

QUESTION 186

When reviewing an active project, an IS auditor observed that, because of a reduction in anticipated benefits and increased costs, the business case was no longer valid. The IS auditor should recommend that the:

- A. project be discontinued.
- B. business case be updated and possible corrective actions be identified.
- C. project be returned to the project sponsor for reapproval.
- D. project be completed and the business case be updated later.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: An IS auditor should not recommend discontinuing or completing the project before reviewing an updated business case. The IS auditor should

recommend that the business case be kept current throughout the project since it is a key input to decisions made throughout the life of any project.

QUESTION 187

An organization is implementing an enterprise resource planning (ERP) application to meet its business objectives. Of the following, who is PRIMARILY responsible for overseeing the project in order to ensure that it

is progressing in accordance with the project plan and that it will deliver the expected results?

- A. Project sponsor
- B. System development project team (SPDT)
- C. Project steering committee
- D. User project team (UPT)

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A project steering committee that provides an overall direction for the enterprise resource planning (ERP) implementation project is responsible for reviewing the project's progress to ensure that it will deliver the expected results. A project sponsor is typically the senior manager in charge of the primary business unit that the application will support. The sponsor provides funding for the project and works closely with the project manager to define the critical success factors or metrics for the project. The project sponsor is not responsible for reviewing the progress of the project. A system development project team (SDPT) completes the assigned tasks, works according to the instructions of the project manager and communicates with the user project team. The SDPT is not responsible for reviewing the progress of the project. A user project team (UPT) completes the assigned tasks, communicates effectively with the system development team and works according to the advice of the project manager. A UPT is not responsible for reviewing the progress of the project.

QUESTION 188

A legacy payroll application is migrated to a new application. Which of the following stakeholders should be PRIMARILY responsible for reviewing and signing-off on the accuracy and completeness of the data before going live?

- A. IS auditor
- B. Database administrator
- C. Project manager
- D. Data owner

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

During the data conversion stage of a project, the data owner is primarily responsible for reviewing and signing-off that the data are migrated completely, accurately and are valid. An IS auditor is not responsible for reviewing and signing-off on the accuracy of the converted data. However, an IS auditor should ensure that there is a review and sign-off by the data owner during the data conversion stage of the project. A database administrator's primary responsibility is to maintain the integrity of the database and make the database available to users. A database administrator is not responsible for reviewing migrated data. A project manager provides day-to-day management and leadership of the project, but is not responsible for the accuracy and integrity of the data.

QUESTION 189

A project manager of a project that is scheduled to take 18 months to complete announces that the project is in a healthy financial position because, after 6 months, only one-sixth of the budget has been spent. The IS auditor should FIRST determine:

- A. what amount of progress against schedule has been achieved.
- B. if the project budget can be reduced.
- C. if the project could be brought in ahead of schedule.
- D. if the budget savings can be applied to increase the project scope.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Cost performance of a project cannot be properly assessed in isolation of schedule performance. Cost cannot be assessed simply in terms of elapsed time on a project. To properly assess the project budget position, it is necessary to know how much progress has actually been made and, given this, what level of expenditure would be expected. It is possible that project expenditure appears to be low because actual progress has been slow. Until the analysis of project against schedule has been completed, it is impossible to know whether there is any reason to reduce budget, if the project has slipped behind schedule, then not only may there be no spare budget but it is possible that extra expenditure may be needed to retrieve the slippage. The low expenditure could actually be representative of a situation where the project is likely to miss deadlines rather than potentially come in ahead of time. If the project is found to be ahead of budget after adjusting for actual progress, this is not necessarily a good outcome because it points to flaws in the original budgeting process; and, as said above, until further analysis is undertaken, it cannot be determined whether any spare funds actually exist. Further, if the project is behind schedule, then adding scope may be the wrong thing to do.

QUESTION 190

A manager of a project was not able to implement all audit recommendations by the target date. The IS auditor should:

- A. recommend that the project be halted until the issues are resolved.
- B. recommend that compensating controls be implemented.
- C. evaluate risks associated with the unresolved issues.
- D. recommend that the project manager reallocate test resources to resolve the issues.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is important to evaluate what the exposure would be when audit recommendations have not been completed by the target date. Based on the evaluation, management can accordingly consider compensating controls, risk acceptance, etc. All other choices might be appropriate only after the risks have been assessed.

QUESTION 191

Which of the following techniques would BEST help an IS auditor gain reasonable assurance that a project can meet its target date?

- A. Estimation of the actual end date based on the completion percentages and estimated time to complete, taken from status reports
- B. Confirmation of the target date based on interviews with experienced managers and staff involved in the completion of the project deliverables.
- C. Extrapolation of the overall end date based on completed work packages and current resources
- D. Calculation of the expected end date based on current resources and remaining available project budget

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Direct observation of results is better than estimations and qualitative information gained from interviews or status reports. Project managers and involved staff tend to underestimate the time needed for completion and the necessary time buffers for dependencies between tasks, while overestimating the completion percentage for tasks underway (80:20 rule). The calculation based on remaining budget does not take into account the speed at which the project has been progressing.

QUESTION 192

Which of the following situations would increase the likelihood of fraud?

- A. Application programmers are implementing changes to production programs.
- B. Application programmers are implementing changes to test programs.
- C. Operations support staff are implementing changes to batch schedules.
- D. Database administrators are implementing changes to data structures.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Production programs are used for processing an enterprise's data. It is imperative that controls on changes to production programs are stringent. Lack of control in this area could result in application programs being modified to manipulate the data. Application programmers are required to implement changes to test programs. These are used only in development and do not directly impact the live processing of data. The implementation of changes to batch schedules by operations support staff will affect the scheduling of the batches only; it does not impact the live data. Database administrators are required to implement changes to data structures. This is required for reorganization of the database to allow for additions, modifications or deletions of fields or tables in the database.

QUESTION 193

The purpose of a checksum on an amount field in an electronic data interchange (EDI) communication of financial transactions is to ensure:

- A. integrity.
- B. authenticity.
- C. authorization.
- D. nonrepudiation.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A checksum calculated on an amount field and included in the EDI communication can be used to identify unauthorized modifications. Authenticity and authorization cannot be established by a checksum alone and need other controls. Nonrepudiation can be ensured by using digital signatures.

QUESTION 194

Before implementing controls, management should FIRST ensure that the controls:

- A. satisfy a requirement in addressing a risk issue.
- B. do not reduce productivity.
- C. are based on a cost-benefit analysis.
- D. are detective or corrective.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When designing controls, it is necessary to consider all the above aspects. In an ideal situation, controls that address all these aspects would be the best controls. Realistically, it may not be possible to design them all and cost may be prohibitive; therefore, it is necessary to first consider the preventive controls that attack the cause of a threat.

QUESTION 195

Information for detecting unauthorized input from a terminal would be BEST provided by the:

- A. console log printout.
- B. transaction journal.
- C. automated suspense file listing.
- D. user error report.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The transaction journal would record all transaction activity, which then could be compared to the authorized source documents to identify any unauthorized input. A console log printout is not the best, because it would not record activity from a specific terminal. An automated suspense file listing would only list transaction activity where an edit error occurred, while the user error report would only list input that resulted in an edit error.

QUESTION 196

The editing/validation of data entered at a remote site would be performed MOST effectively at the:

- A. central processing site after running the application system.

- B. central processing site during the running of the application system.
- C. remote processing site after transmission of the data to the central processing site.
- D. remote processing site prior to transmission of the data to the central processing site.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is important that the data entered from a remote site is edited and validated prior to transmission to the central processing site.

QUESTION 197

To reduce the possibility of losing data during processing, the FIRST point at which control totals should be implemented is:

- A. during data preparation.
- B. in transit to the computer.
- C. between related computer runs.
- D. during the return of the data to the user department.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

During data preparation is the best answer, because it establishes control at the earliest point.

QUESTION 198

Functional acknowledgements are used:

- A. as an audit trail for EDI transactions.
- B. to functionally describe the IS department.
- C. to document user roles and responsibilities.
- D. as a functional description of application software.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Functional acknowledgements are standard EDI transactions that tell trading partners that their electronic documents were received. Different types of functional acknowledgements provide various levels of detail and, therefore, can act as an audit trail for EDI transactions. The other choices are not relevant to the description of functional acknowledgements.

QUESTION 199

A proposed transaction processing application will have many data capture sources and outputs in paper and electronic form. To ensure that transactions are not lost during processing, an IS auditor should recommend the inclusion of:

- A. validation controls.
- B. internal credibility checks.
- C. clerical control procedures.
- D. automated systems balancing.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Automated systems balancing would be the best way to ensure that no transactions are lost as any imbalance between total inputs and total outputs would be reported for investigation and correction. Validation controls and internal credibility checks are certainly valid controls, but will not detect and report lost transactions. In addition, although a clerical procedure could be used to summarize and compare inputs and outputs, an automated process is less susceptible to error.

QUESTION 200

What process uses test data as part of a comprehensive test of program controls in a continuous online manner?

- A. Test data/deck
- B. Base-case system evaluation
- C. Integrated test facility (ITF)
- D. Parallel simulation

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A base-case system evaluation uses test data sets developed as part of comprehensive testing programs, it is used to verify correct systems operations before acceptance, as well as periodic validation. Test data/deck simulates transactions through real programs. An ITF creates fictitious files in the database with test transactions processed simultaneously with live input. Parallel simulation is the production of data processed using computer programs that simulate application program logic.

QUESTION 201

What control detects transmission errors by appending calculated bits onto the end of each segment of data?

- A. Reasonableness check
- B. Parity check
- C. Redundancy check
- D. Check digits

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A redundancy check detects transmission errors by appending calculated bits onto the end of each segment of data. A reasonableness check compares data to predefined reasonableness limits or occurrence rates established for the data. A parity check is a hardware control that detects data errors when data are read from one computer to another, from memory or during transmission. Check digits detect transposition and transcription errors.

QUESTION 202

Which of the following is the GREATEST risk when implementing a data warehouse?

- A. increased response time on the production systems
- B. Access controls that are not adequate to prevent data modification
- C. Data duplication
- D. Data that is not updated or current

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Once the data is in a warehouse, no modifications should be made to it and access controls should be in place to prevent data modification. Increased response time on the production systems is not a risk, because a data warehouse does not impact production data. Based on data replication, data duplication is inherent in a data warehouse. Transformation of data from operational systems to a data warehouse is done at predefined intervals, and as such, data may not be current.

QUESTION 203

Which of the following will BEST ensure the successful offshore development of business applications?

- A. Stringent contract management practices
- B. Detailed and correctly applied specifications
- C. Awareness of cultural and political differences
- D. Post implementation reviews

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When dealing with offshore operations, it is essential that detailed specifications be created. Language differences and a lack of interaction between developers and physically remote end users could create gaps in communication in which assumptions and modifications may not be adequately communicated. Contract management practices, cultural and political differences, and post implementation reviews, although important, are not as pivotal to the success of the project.

QUESTION 204

Which of the following is the GREATEST risk to the effectiveness of application system controls?

- A. Removal of manual processing steps
- B. inadequate procedure manuals
- C. Collusion between employees
- D. Unresolved regulatory compliance issues

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Collusion is an active attack that can be sustained and is difficult to identify since even well-thought-out application controls may be circumvented. The other choices do not impact well-designed application controls.

QUESTION 205

The MAIN purpose of a transaction audit trail is to:

- A. reduce the use of storage media.
- B. determine accountability and responsibility for processed transactions.
- C. help an IS auditor trace transactions.
- D. provide useful information for capacity planning.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Enabling audit trails aids in establishing the accountability and responsibility for processed transactions by tracing them through the information system. Enabling audit trails increases the use of disk space. A transaction log file would be used to trace transactions, but would not aid in determining accountability and responsibility. The objective of capacity planning is the efficient and effective use of IT resources and requires

information such as CPU utilization, bandwidth, number of users, etc.

QUESTION 206

An appropriate control for ensuring the authenticity of orders received in an EDI application is to:

- A. acknowledge receipt of electronic orders with a confirmation message.
- B. perform reasonableness checks on quantities ordered before filling orders.
- C. verify the identity of senders and determine if orders correspond to contract terms.
- D. encrypt electronic orders.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An electronic data interchange (EDI) system is subject not only to the usual risk exposures of computer systems but also to those arising from the potential ineffectiveness of controls on the part of the trading partner and the third-party service provider, making authentication of users and messages a major security concern. Acknowledging the receipt of electronic orders with a confirming message is good practice but will not authenticate orders from customers. Performing reasonableness checks on quantities ordered before placing orders is a control for ensuring the correctness of the company's orders, not the authenticity of its customers' orders. Encrypting sensitive messages is an appropriate step but does not apply to messages received.

QUESTION 207

A manufacturing firm wants to automate its invoice payment system. Objectives state that the system should require considerably less time for review and authorization and the system should be capable of identifying errors that require follow up. Which of the following would BEST meet these objectives?

- A. Establishing an inter-networked system of client servers with suppliers for increased efficiencies
- B. Outsourcing the function to a firm specializing in automated payments and accounts receivable/invoice processing
- C. Establishing an EDI system of electronic business documents and transactions with key suppliers, computer to computer, in a standard format
- D. Reengineering the existing processing and redesigning the existing system

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

EDI is the best answer. Properly implemented (e.g., agreements with trading partner's transaction standards, controls over network security mechanisms in conjunction with application controls), EDI is best suited to identify and follow up on errors more quickly, given reduced opportunities for review and authorization.

QUESTION 208

An IS auditor is told by IS management that the organization has recently reached the highest level of the software capability maturity model (CMM). The software quality process MOST recently added by the organization is:

- A. continuous improvement.
- B. quantitative quality goals.
- C. a documented process.
- D. a process tailored to specific projects.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An organization would have reached the highest level of the software CMM at level 5, optimizing. Quantitative quality goals can be reached at level 4 and below, a documented process is executed at level 3 and below, and a process tailored to specific projects can be achieved at level 3 or below.

QUESTION 209

During the audit of an acquired software package, an IS auditor learned that the software purchase was based on information obtained through the Internet, rather than from responses to a request for proposal (RFP). The IS auditor should FIRST:

- A. test the software for compatibility with existing hardware.
- B. perform a gap analysis.
- C. review the licensing policy.
- D. ensure that the procedure had been approved.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In the case of a deviation from the predefined procedures, an IS auditor should first ensure that the procedure followed for acquiring the software is consistent with the business objectives and has been approved by the appropriate authorities. The other choices are not the first actions an IS auditor should take. They are steps that may or may not be taken after determining that the procedure used to acquire the software had been approved.

QUESTION 210

Failure in which of the following testing stages would have the GREATEST impact on the implementation of new application software?

- A. System testing
- B. Acceptance testing
- C. Integration testing
- D. Unit testing

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Acceptance testing is the final stage before the software is installed and is available for use. The greatest impact would occur if the software fails at the acceptance testing level, as this could result in delays and cost overruns. System testing is undertaken by the developer team to determine if the software meets user requirements per specifications. Integration testing examines the units/modules as one integrated system and unit testing examines the individual units or components of the software. System, integration and unit testing are all performed by the developers at various stages of development; the impact of failure is comparatively less for each than failure at the acceptance testing stage.

QUESTION 211

An organization has an integrated development environment (IDE) on which the program libraries reside on

the server, but modification/development and testing are done from PC workstations. Which of the following would be a strength of an IDE?

- A. Controls the proliferation of multiple versions of programs
- B. Expands the programming resources and aids available
- C. Increases program and processing integrity

D. Prevents valid changes from being overwritten by other changes

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A strength of an IDE is that it expands the programming resources and aids available. The other choices are IDE weaknesses.

QUESTION 212

Which of the following is the most important element in the design of a data warehouse?

- A. Quality of the metadata
- B. Speed of the transactions
- C. Volatility of the data
- D. Vulnerability of the system

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Quality of the metadata is the most important element in the design of a data warehouse. A data warehouse is a copy of transaction data specifically structured for query and analysis. Metadata aim to provide a table of contents to the information stored in the data warehouse. Companies that have built warehouses believe that metadata are the most important component of the warehouse.

QUESTION 213

Ideally, stress testing should be carried out in a:

- A. test environment using test data.
- B. production environment using live workloads.
- C. test environment using live workloads.
- D. production environment using test data.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Stress testing is carried out to ensure a system can cope with production workloads. A test environment should always be used to avoid damaging the production environment. Hence, testing should never take place in a production environment (choices Band D), and if only test data is used, there is no certainty that the system was stress tested adequately.

QUESTION 214

Which of the following is an object-oriented technology characteristic that permits an enhanced degree of security over data?

- A. inheritance
- B. Dynamic warehousing
- C. Encapsulation
- D. Polymorphism

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Encapsulation is a property of objects, and it prevents accessing either properties or methods that have not been previously defined as public. This means that any implementation of the behavior of an object is not accessible. An object defines a communication interface with the exterior and only that which belongs to that interface can be accessed.

QUESTION 215

The phases and deliverables of a system development life cycle (SDLC) project should be determined:

- A. during the initial planning stages of the project.
- B. after early planning has been completed, but before work has begun.
- C. throughout the work stages, based on risks and exposures.
- D. only after all risks and exposures have been identified and the IS auditor has recommended appropriate controls.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is extremely important that the project be planned properly and that the specific phases and deliverables be identified during the early stages of the project.

QUESTION 216

Which of the following is a management technique that enables organizations to develop strategically important systems faster, while reducing development costs and maintaining quality?

- A. Function point analysis
- B. Critical path methodology
- C. Rapid application development
- D. Program evaluation review technique

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Rapid application development is a management technique that enables organizations to develop strategically important systems faster, while reducing development costs and maintaining quality. The program evaluation review technique (PERT) and critical path methodology (CPM) are both planning and control techniques, while function point analysis is used for estimating the complexity of developing business applications.

QUESTION 217

When implementing an application software package, which of the following presents the GREATEST risk?

- A. Uncontrolled multiple software versions
- B. Source programs that are not synchronized with object code
- C. incorrectly set parameters
- D. Programming errors.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Parameters that are not set correctly would be the greatest concern when implementing an application software package. The other choices, though important, are a concern of the provider, not the organization that is implementing the software itself.

QUESTION 218

Which of the following is an advantage of prototyping?

- A. The finished system normally has strong internal controls.
- B. Prototype systems can provide significant time and cost savings.
- C. Change control is often less complicated with prototype systems.
- D. it ensures that functions or extras are not added to the intended system.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 219

A decision support system (DSS):

- A. is aimed at solving highly structured problems.
- B. combines the use of models with nontraditional data access and retrieval functions.
- C. emphasizes flexibility in the decision making approach of users.
- D. supports only structured decision making tasks.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

DSS emphasizes flexibility in the decision making approach of users. It is aimed at solving less structured problems, combines the use of models and analytic techniques with traditional data access and retrieval functions, and supports semi structured decision making tasks.

QUESTION 220

An advantage of using sanitized live transactions in test data is that:

- A. all transaction types will be included.
- B. every error condition is likely to be tested.
- C. no special routines are required to assess the results.
- D. test transactions are representative of live processing.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Test data will be representative of live processing; however, it is unlikely that all transaction types or error conditions will be tested in this way.

QUESTION 221

An IS auditor's PRIMARY concern when application developers wish to use a copy of yesterday's production transaction file for volume tests is that:

- A. users may prefer to use contrived data for testing.
- B. unauthorized access to sensitive data may result.
- C. error handling and credibility checks may not be fully proven.
- D. the full functionality of the new process may not necessarily be tested.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Unless the data are sanitized, there is a risk of disclosing sensitive data.

QUESTION 222

Which of the following is the PRIMARY purpose for conducting parallel testing?

- A. To determine if the system is cost-effective
- B. To enable comprehensive unit and system testing
- C. To highlight errors in the program interfaces with files
- D. To ensure the new system meets user requirements

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The purpose of parallel testing is to ensure that the implementation of a new system will meet user requirements. Parallel testing may show that the old system is, in fact, better than the new system, but this is not the primary reason. Unit and system are completed before parallel testing. Program interfaces with files are tested for errors during system testing.

QUESTION 223

The knowledge base of an expert system that uses questionnaires to lead the user through a series of choices before a conclusion is reached is known as:

- A. rules.
- B. decision trees.
- C. semantic nets.
- D. dataflow diagrams.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Decision trees use questionnaires to lead a user through a series of choices until a conclusion is reached. Rules refer to the expression of declarative knowledge through the use of if-then relationships. Semantic nets consist of a graph in which nodes represent physical or conceptual objects and the arcs describe the relationship between the nodes. Semantic nets resemble a dataflow diagram and make use of an inheritance mechanism to prevent duplication of data.

QUESTION 224

An advantage in using a bottom-up vs. a top-down approach to software testing is that:

- A. interface errors are detected earlier.
- B. confidence in the system is achieved earlier.
- C. errors in critical modules are detected earlier.
- D. major functions and processing are tested earlier.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The bottom-up approach to software testing begins with the testing of atomic units, such as programs and modules, and works upward until a complete system testing has taken place. The advantages of using a bottom-up approach to software testing are the fact that there is no need for stubs or drivers and errors in critical modules are found earlier. The other choices in this question all refer to advantages of a top-down approach, which follows the opposite path, either in depth-first or breadth-first search order.

QUESTION 225

During which of the following phases in system development would user acceptance test plans normally be prepared?

- A. Feasibility study
- B. Requirements definition
- C. implementation planning
- D. Postimplementation review

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

During requirements definition, the project team will be working with the users to define their precise objectives and functional needs. At this time, the users should be working with the team to consider and document how the system functionality can be tested ensure it meets their stated needs. The feasibility study is too early for such detailed user involvement, and the implementation planning and postimplementation review phases are too late. An IS auditor should know at what point user testing should be planned to ensure it is most effective and efficient.

QUESTION 226

The use of object-oriented design and development techniques would MOST likely:

- A. facilitate the ability to reuse modules.
- B. improve system performance.
- C. enhance control effectiveness.
- D. speed up the system development life cycle.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

One of the major benefits of object-oriented design and development is the ability to reuse modules. The other options do not normally benefit from the object-oriented technique.

QUESTION 227

Which of the following should be included in a feasibility study for a project to implement an EDI process?

- A. The encryption algorithm format
- B. The detailed internal control procedures
- C. The necessary communication protocols
- D. The proposed trusted third-party agreement

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Encryption algorithms, third-party agreements and internal control procedures are too detailed for this phase. They would only be outlined and any cost or performance implications shown. The communications protocols must be included, as there may be significant cost implications if new hardware and software are involved, and risk implications if the technology is new to the organization.

QUESTION 228

When a new system is to be implemented within a short time frame, it is MOST important to:

- A. finish writing user manuals.
- B. perform user acceptance testing.
- C. add last-minute enhancements to functionalities.
- D. ensure that the code has been documented and reviewed.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

It would be most important to complete the user acceptance testing to ensure that the system to be implemented is working correctly. The completion of the user manuals is similar to the performance of code reviews. If time is tight, the last thing one would want to do is add another enhancement, as it would be necessary to freeze the code and complete the testing, then make any other changes as future enhancements. It would be appropriate to have the code documented and reviewed, but unless the

acceptance testing is completed, there is no guarantee that the system will work correctly and meet user requirement.

QUESTION 229

An organization has contracted with a vendor for a turnkey solution for their electronic toll collection system (ETCS). The vendor has provided its proprietary application software as part of the solution. The contract should require that:

- A. a backup server be available to run ETCS operations with up-to-date data.
- B. a backup server be loaded with all the relevant software and data.
- C. the systems staff of the organization be trained to handle any event.
- D. source code of the ETCS application be placed in escrow.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Whenever proprietary application software is purchased, the contract should provide for a source code agreement. This will ensure that the purchasing company will have the opportunity to modify the software should the vendor cease to be in business. Having a backup server with current data and staff training is critical but not as critical as ensuring the availability of the source code.

QUESTION 230

The MOST likely explanation for the use of applets in an Internet application is that:

- A. it is sent over the network from the server.
- B. the server does not run the program and the output is not sent over the network.
- C. they improve the performance of the web server and network.
- D. it is a JAVA program downloaded through the web browser and executed by the web server of the client machine.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

An applet is a JAVA program that is sent over the network from the web server, through a web browser and to the client machine; the code is then run on the machine. Since the server does not run the program and the output is not sent over the network, the performance on the web server and network-over which the server and client are connected-dramatically improves through the use of applets. Performance improvement is more important than the reasons offered in choices A and B. Since JAVA virtual machine (JVM) is embedded in most web browsers, the applet download through the web browser runs on the client machine from the web browser, not from the web server, making choice D incorrect.

QUESTION 231

Which of the following systems or tools can recognize that a credit card transaction is more likely to have resulted from a stolen credit card than from the holder of the credit card?

- A. Intrusion detection systems
- B. Data mining techniques
- C. Firewalls
- D. Packet filtering routers

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Data mining is a technique used to detect trends or patterns of transactions or data. If the historical pattern of charges against a credit card account is changed, then it is a flag that the transaction may have resulted from a fraudulent use of the card.

QUESTION 232

Functionality is a characteristic associated with evaluating the quality of software products throughout their life cycle, and is BEST described as the set of attributes that bear on the:

- A. existence of a set of functions and their specified properties.
- B. ability of the software to be transferred from one environment to another.
- C. capability of software to maintain its level of performance under stated conditions.
- D. relationship between the performance of the software and the amount of resources used.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Functionality is the set of attributes that bears on the existence of a set of functions and their specified properties. The functions are those that satisfy stated or implied needs. Choice B refers to portability; choice C refers to reliability and choice D refers to efficiency.

QUESTION 233

During the development of an application, the quality assurance testing and user acceptance testing were combined. The MAJOR concern for an IS auditor reviewing the project is that there will be:

- A. increased maintenance.
- B. improper documentation of testing.
- C. inadequate functional testing.
- D. delays in problem resolution.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The major risk of combining quality assurance testing and user acceptance testing is that functional testing may be inadequate. Choices A, B and D are not as important.

QUESTION 234

The GREATEST advantage of rapid application development (RAD) over the traditional system development life cycle (SDLC) is that it:

- A. facilitates user involvement.
- B. allows early testing of technical features.
- C. facilitates conversion to the new system.
- D. shortens the development time frame.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The greatest advantage of RAD is the shorter time frame for the development of a system. Choices A and B are true, but they are also true for the traditional systems development life cycle. Choice C is not necessarily always true.

QUESTION 235

An IS auditor reviewing a proposed application software acquisition should ensure that the:

- A. operating system (OS) being used is compatible with the existing hardware platform.
- B. planned OS updates have been scheduled to minimize negative impacts on company needs.
- C. OS has the latest versions and updates.
- D. products are compatible with the current or planned OS.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Choices A, B and C are incorrect because none of them are related to the area being audited. In reviewing the proposed application, the auditor should ensure that the products to be purchased are compatible with the current or planned OS. Regarding choice, A, if the OS is currently being used, it is compatible with the existing hardware platform, because if it is not it would not operate properly. In choice B, the planned OS updates should be scheduled to minimize negative impacts on the organization. For choice C, the installed OS should be equipped with the most recent versions and updates (with sufficient history and stability).

QUESTION 236

The GREATEST benefit in implementing an expert system is the:

- A. capturing of the knowledge and experience of individuals in an organization.
- B. sharing of knowledge in a central repository.
- C. enhancement of personnel productivity and performance.
- D. reduction of employee turnover in key departments.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The basis for an expert system is the capture and recording of the knowledge and experience of individuals in an organization. Coding and entering the knowledge in a central repository, shareable within the enterprise, is a means of facilitating the expert system. Enhancing personnel productivity and performance is a benefit; however, it is not as important as capturing the knowledge and experience. Employee turnover is not necessarily affected by an expert system.

QUESTION 237

By evaluating application development projects against the capability maturity model (CMM), an IS auditor should be able to verify that:

- A. reliable products are guaranteed.
- B. programmers' efficiency is improved.
- C. security requirements are designed.
- D. predictable software processes are followed.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

By evaluating the organization's development projects against the CMM, an IS auditor determines whether the development organization follows a stable, predictable software process. Although the likelihood of success should increase as the software processes mature toward the optimizing level, mature processes do not guarantee a reliable product. CMM does not evaluate technical processes such as programming nor does it evaluate security requirements or other application controls.

QUESTION 238

The waterfall life cycle model of software development is most appropriately used when:

- A. requirements are well understood and are expected to remain stable, as is the business environment in which the system will operate.
- B. requirements are well understood and the project is subject to time pressures.
- C. the project intends to apply an object-oriented design and programming approach.
- D. the project will involve the use of new technology.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Historically, the waterfall model has been best suited to the stable conditions described in choice A. When the degree of uncertainty of the system to be delivered and the conditions in which it will be used rises, the waterfall model has not been successful, in these circumstances, the various forms of iterative development life cycle gives the advantage of breaking down the scope of the overall system to be delivered, making the requirements gathering and design activities more manageable. The ability to deliver working software earlier also acts to alleviate uncertainty and may allow an earlier realization of benefits. The choice of a design and programming approach is not itself a determining factor of the type of software development life cycle that is appropriate. The use of new technology in a project introduces a significant element of risk. An iterative form of development, particularly one of the agile methods that focuses on early development of actual working software, is likely to be the better option to manage this uncertainty.

QUESTION 239

Which of the following is MOST critical when creating data for testing the logic in a new or modified application system?

- A. A sufficient quantity of data for each test case
- B. Data representing conditions that are expected in actual processing
- C. Completing the test on schedule
- D. A random sample of actual data

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: Selecting the right kind of data is key in testing a computer system. The data should not only include valid and invalid data but should be representative of actual processing; quality is more important than quantity. It is more important to have adequate test data than to complete the testing on schedule. It is unlikely that a random sample of actual data would cover all test conditions and provide a reasonable representation of actual data.

QUESTION 240

During the review of a web-based software development project, an IS auditor realizes that coding standards are not enforced and code reviews are rarely carried out. This will MOST likely increase the likelihood of a successful:

- A. buffer overflow.
- B. brute force attack.
- C. distributed denial-of-service attack.
- D. war dialing attack.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Poorly written code, especially in web-based applications, is often exploited by hackers using buffer overflow techniques. A brute force attack is used to crack passwords. A distributed denial- of-service attack floods its target with numerous packets, to prevent it from responding to legitimate requests. War dialing uses modem- scanning tools to hack PBXs.

QUESTION 241

Which testing approach is MOST appropriate to ensure that internal application interface errors are identified as soon as possible?

- A. Bottom up
- B. Sociability testing
- C. Top-down
- D. System test

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The top-down approach to testing ensures that interface errors are detected early and that testing of major functions is conducted early. A bottom-up approach to testing begins with atomic units, such as programs and modules, and works upward until a complete system test has taken place. Sociability testing and system tests take place at a later stage in the development process.

QUESTION 242

During the requirements definition phase of a software development project, the aspects of software testing that should be addressed are developing:

- A. test data covering critical applications.
- B. detailed test plans.
- C. quality assurance test specifications.
- D. user acceptance testing specifications

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: A key objective in any software development project is to ensure that the developed software will meet the business objectives and the requirements of the user. The users should be involved in the requirements definition phase of a development project and user acceptance test specification should be developed during this phase. The other choices are generally performed during the system testing phase.

QUESTION 243

Which of the following is an advantage of the top-down approach to software testing?

- A. Interface errors are identified early
- B. Testing can be started before all programs are complete
- C. it is more effective than other testing approaches
- D. Errors in critical modules are detected sooner

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The advantage of the top-down approach is that tests of major functions are conducted early, thus enabling the detection of interface errors sooner. The most effective testing approach is dependent on the environment being tested. Choices B and D are advantages of the bottom-up approach to system testing.

QUESTION 244

During the system testing phase of an application development project the IS auditor should review the:

- A. conceptual design specifications.
- B. vendor contract.
- C. error reports.
- D. program change requests.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Testing is crucial in determining that user requirements have been validated. The IS auditor should be involved in this phase and review error reports for their precision in recognizing erroneous data and review the procedures for resolving errors. A conceptual design specification is a document prepared during the requirements definition phase. A vendor contract is prepared during a software acquisition process. Program change requests would normally be reviewed as a part of the postimplementation phase.

QUESTION 245

Which of the following would be the MOST cost-effective recommendation for reducing the number of defects encountered during software development projects?

- A. increase the time allocated for system testing
- B. implement formal software inspections
- C. increase the development staff
- D. Require the sign-off of all project deliverables

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Explanation: inspections of code and design are a proven software quality technique. An advantage of this approach is that defects are identified before they propagate through the development life cycle. This reduces the cost of correction as less rework is involved. Allowing more time for testing may discover more defects; however, little is revealed as to why the quality problems are occurring and the cost of the extra testing, and the cost of rectifying the defects found will be greater than if they had been discovered earlier in the development process. The ability of the development staff can have a bearing on the quality of what is produced; however, replacing staff can be expensive and disruptive, and the presence of a competent staff cannot guarantee quality in the absence of effective quality management processes. Sign-off of deliverables may help detect defects if signatories are diligent about reviewing deliverable content; however, this is difficult to enforce.

Deliverable reviews normally do not go down to the same level of detail as software inspections.

QUESTION 246

Which of the following is a prevalent risk in the development of end-user computing (EUC) applications?

- A. Applications may not be subject to testing and IT general controls
- B. increased development and maintenance costs
- C. increased application development time
- D. Decision-making may be impaired due to diminished responsiveness to requests for information

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

End-user developed applications may not be subjected to an independent outside review by systems analysts and frequently are not created in the context of a formal development methodology. These applications may lack appropriate standards, controls, quality assurance procedures, and documentation. A risk of end-user applications is that management may rely on them as much as traditional applications. End-user computing (EUC) systems typically result in reduced application development and maintenance costs, and a reduced development cycle time. EUC systems normally increase flexibility and responsiveness to management's information requests.

QUESTION 247

Normally, it would be essential to involve which of the following stakeholders in the initiation stage of a project?

- A. System owners
- B. System users
- C. System designers
- D. System builders

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

System owners are the information systems (project) sponsors or chief advocates. They normally are responsible for initiating and funding projects to develop, operate and maintain information systems. System users are the individuals who use or are affected by the information system.

Their requirements are crucial in the testing stage of a project. System designers translate business requirements and constraints into technical solutions. System builders construct the system based on the specifications from the systems designers. In most cases, the designers and builders are one and the same.

QUESTION 248

The MAJOR advantage of a component-based development approach is the:

- A. ability to manage an unrestricted variety of data types.
- B. provision for modeling complex relationships.
- C. capacity to meet the demands of a changing environment.
- D. support of multiple development environments.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Components written in one language can interact with components written in other languages or running on other machines, which can increase the speed of development. Software developers can then focus on business logic. The other choices are not the most significant advantages of a component-based development approach.

QUESTION 249

The specific advantage of white box testing is that it:

- A. verifies a program can operate successfully with other parts of the system.
- B. ensures a program's functional operating effectiveness without regard to the internal program structure.
- C. determines procedural accuracy or conditions of a program's specific logic paths.
- D. examines a program's functionality by executing it in a tightly controlled or virtual environment with restricted access to the host system.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

White box testing assesses the effectiveness of software program logic. Specifically, test data are used in determining procedural accuracy or conditions of a program's logic paths. Verifying the program can operate successfully with other parts of the system is sociability testing. Testing the program's functionality without knowledge of internal structures is black box testing. Controlled testing of programs in a semi-debugged environment, either heavily controlled step-by-step or via monitoring in virtual machines, is sand box testing.

QUESTION 250

Following best practices, formal plans for implementation of new information systems are developed during the:

- A. development phase.
- B. design phase.
- C. testing phase.
- D. deployment phase.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Planning for implementation should begin well in advance of the actual implementation date. A formal implementation plan should be constructed in the design phase and revised as the development progresses.

QUESTION 251

An IS auditor is reviewing a project that is using an Agile software development approach. Which of the following should the IS auditor expect to find?

- A. Use a process-based maturity model such as the capability maturity model (CMM)
- B. Regular monitoring of task-level progress against schedule
- C. Extensive use of software development tools to maximize team productivity
- D. Postiteration reviews that identify lessons learned for future use in the project

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A key tenet of the Agile approach to software project management is team learning and the use of team learning to refine project management and software development processes as the project progresses. One of the best ways to achieve this is that, at the end of each iteration, the team considers and documents what worked well and what could have worked better, and identifies improvements to be implemented in subsequent iterations. CMM and Agile really sit at opposite poles. CMM places heavy emphasis on predefined formal processes and formal project management and software development deliverables. Agile projects, by contrast, rely on refinement of process as dictated by the particular needs of the project and team dynamics. Additionally, less importance is placed on formal paper-based deliverables, with the preference being effective informal communication within the team and with key outside contributors. Agile projects produce releasable software in short iterations, typically ranging from 4 to 8 weeks. This, in itself, instills considerable performance discipline within the team. This, combined with short daily meetings to agree on what the team is doing and the identification of any impediments, renders task-level tracking against a schedule redundant. Agile projects do make use of suitable development tools; however, tools are not seen as the primary means of achieving productivity. Team harmony, effective communications and collective ability to solve challenges are of greater importance.

QUESTION 252

An IS auditor finds that user acceptance testing of a new system is being repeatedly interrupted as defect fixes are implemented by developers. Which of the following would be the BEST recommendation for an IS auditor to make?

- A. Consider feasibility of a separate user acceptance environment
- B. Schedule user testing to occur at a given time each day
- C. implement a source code version control tool
- D. Only retest high priority defects

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A separate environment or environments is normally necessary for testing to be efficient and effective, and to ensure the integrity of production code, it is important that the development and testing code base be separate. When defects are identified they can be fixed in the development environment, without interrupting testing, before being migrated in a controlled manner to the test environment. A separate test environment can

also be used as the final staging area from which code is migrated to production. This enforces a separation between development and production code. The logistics of setting up and refreshing customized test data is easier if a separate environment is maintained. If developers and testers are sharing the same environment, they have to work effectively at separate times of the day. It is unlikely that this would provide optimum productivity. Use of a source code control tool is a good practice, but it does not properly mitigate the lack of an appropriate testing environment. Even low priority fixes run the risk of introducing unintended results when combined with the rest of the system code. To prevent this, regular regression testing covering all code changes should occur. A separate test environment makes the logistics of regression testing easier to manage.

QUESTION 253

Which of the following types of testing would determine whether a new or modifies system can operate in its target environment without adversely impacting other existing systems?

- A. Parallel testing
- B. Pilot testing
- C. Interface/integration testing
- D. Sociability testing

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The purpose of sociability testing is to confirm that a new or modified system can operate in its target environment without adversely impacting existing systems. This should cover the platform that will perform primary application processing and interfaces with other systems, as well as changes to the desktop in a client-server or web development. Parallel testing is the process of feeding data into two systems-the modified system and an alternate system- and comparing the results. In this approach, the old and new systems operate concurrently for a period of time and perform the same processing functions. Pilot testing takes place first at one location and is then extended to other locations. The purpose is to see if the new system operates satisfactorily in one place before implementing it at other locations. Interface/integration testing is a hardware or software test that evaluates the connection of two or more components that pass information from one area to another. The objective is to take unit-tested modules and build an integrated structure.

QUESTION 254

At the end of the testing phase of software development, an IS auditor observes that an intermittent software error has not been corrected. No action has been taken to resolve the error. The IS auditor should:

- A. report the error as a finding and leave further exploration to the auditee's discretion.
- B. attempt to resolve the error.
- C. recommend that problem resolution be escalated.
- D. ignore the error, as it is not possible to get objective evidence for the software error.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When an IS auditor observes such conditions, it is best to fully apprise the auditee and suggest that further problem resolutions be attempted. Recording it as a minor error and leaving it to the auditee's discretion would be inappropriate, and neglecting the error would indicate that the auditor has not taken steps to further probe the issue to its logical end.

QUESTION 255

Which of the following is an implementation risk within the process of decision support systems?

- A. Management control
- B. Semistructured dimensions
- C. inability to specify purpose and usage patterns
- D. Changes in decision processes

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The inability to specify purpose and usage patterns is a risk that developers need to anticipate while implementing a decision support system (DSS). Choices A, B and D are not risks, but characteristics of a DDS.

QUESTION 256

An organization is implementing a new system to replace a legacy system. Which of the following conversion practices creates the GREATEST risk?

- A. Pilot
- B. Parallel
- C. Direct cutover
- D. Phased

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Direct cutover implies switching to the new system immediately, usually without the ability to revert to the old system in the event of problems. All other alternatives are done gradually and thus provide greater recoverability and are therefore less risky.

QUESTION 257

Which of the following system and data conversion strategies provides the GREATEST redundancy?

- A. Direct cutover
- B. Pilot study
- C. Phased approach
- D. Parallel run

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Parallel runs are the safest though the most expensive approach, because both the old and new systems are run, thus incurring what might appear to be double costs. Direct cutover is actually quite risky, since it does not provide for a 'shake down period' nor does it provide an easy fallback option. Both a pilot study and a phased approach are performed incrementally, making rollback procedures difficult to execute.

QUESTION 258

Which of the following would impair the independence of a quality assurance team?

- A. Ensuring compliance with development methods
- B. Checking the testing assumptions
- C. Correcting coding errors during the testing process
- D. Checking the code to ensure proper documentation

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Correction of code should not be a responsibility of the quality assurance team as it would not ensure segregation of duties and would impair the team's independence. The other choices are valid quality assurance functions.

QUESTION 259

From a risk management point of view, the BEST approach when implementing a large and complex IT infrastructure is:

- A. a big bang deployment after proof of concept.
- B. prototyping and a one-phase deployment.
- C. a deployment plan based on sequenced phases.
- D. to simulate the new infrastructure before deployment.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When developing a large and complex IT infrastructure, the best practice is to use a phased approach to fitting the entire system together. This will provide greater assurance of quality results. The other choices are riskier approaches.

QUESTION 260

An organization is migrating from a legacy system to an enterprise resource planning (ERP) system. While reviewing the data migration activity, the MOST important concern for the IS auditor is to determine that there is a:

- A. correlation of semantic characteristics of the data migrated between the two systems.
- B. correlation of arithmetic characteristics of the data migrated between the two systems.
- C. correlation of functional characteristics of the processes between the two systems.
- D. relative efficiency of the processes between the two systems.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Due to the fact that the two systems could have a different data representation, including the database schema, the IS auditor's main concern should be to verify that the interpretation of the data is the same in the new as it was in the old system. Arithmetic characteristics represent aspects of data structure and internal definition in the database, and therefore are less important than the semantic characteristics. A review of the

correlation of the functional characteristics or a review of the relative efficiencies of the processes between the two systems is not relevant to a data migration review.

QUESTION 261

The reason a certification and accreditation process is performed on critical systems is to ensure that:

- A. security compliance has been technically evaluated.
- B. data have been encrypted and are ready to be stored.
- C. the systems have been tested to run on different platforms.
- D. the systems have followed the phases of a waterfall model.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Certified and accredited systems are systems that have had their security compliance technically evaluated for running on a specific production server. Choice B is incorrect because not all data of certified systems are encrypted. Choice C is incorrect because certified systems are evaluated to run in a specific environment. A

waterfall model is a software development methodology and not a reason for performing a certification and accrediting process.

QUESTION 262

During a postimplementation review of an enterprise resource management system, an IS auditor would MOST likely:

- A. review access control configuration
- B. evaluate interface testing.
- C. review detailed design documentation.
- D. evaluate system testing.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Reviewing access control configuration would be the first task performed to determine whether security has been appropriately mapped in the system. Since a postimplementation review is done after user acceptance testing and actual implementation, one would not engage in interface testing or detailed design documentation. Evaluating interface testing would be part of the implementation process. The issue of reviewing detailed design documentation is not generally relevant to an enterprise resource management system, since these are usually vendor packages with user manuals. System testing should be performed before final user signoff.

QUESTION 263

During an application audit, an IS auditor finds several problems related to corrupted data in the database. Which of the following is a corrective control that the IS auditor should recommend?

- A. Implement data backup and recovery procedures.
- B. Define standards and closely monitor for compliance.
- C. Ensure that only authorized personnel can update the database.
- D. Establish controls to handle concurrent access problems.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Implementing data backup and recovery procedure is a corrective control, because backup and recovery procedures can be used to roll back database errors. Defining or establishing standards is a preventive control, while monitoring for compliance is a detective control. Ensuring that only authorized personnel can update the database is a preventive control. Establishing controls to handle concurrent access problems is also a preventive control.

QUESTION 264

An IS auditor finds out-of-range data in some tables of a database. Which of the following controls should the IS auditor recommend to avoid this situation?

- A. Log all table update transactions.
- B. implement before-and-after image reporting.
- C. Use tracing and tagging.
- D. implement integrity constraints in the database.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Implementing integrity constraints in the database is a preventive control, because data is checked against predefined tables or rules preventing any undefined data from being entered. Logging all table update transactions and implementing before-and-after image reporting are detective controls that would not avoid the situation. Tracing and tagging are used to test application systems and controls and could not prevent out-of-range data.

QUESTION 265

Responsibility and reporting lines cannot always be established when auditing automated systems since:

- A. diversified control makes ownership irrelevant.
- B. staff traditionally changes jobs with greater frequency.
- C. ownership is difficult to establish where resources are shared.
- D. duties change frequently in the rapid development of technology.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Because of the diversified nature of both data and application systems, the actual owner of data and applications may be hard to establish.

QUESTION 266

In an online transaction processing system, data integrity is maintained by ensuring that a transaction is either completed in its entirety or not at all. This principle of data integrity is known as:

- A. isolation.
- B. consistency.
- C. atomicity.
- D. durability.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The principle of atomicity requires that a transaction be completed in its entirety or not at all. If an error or interruption occurs, all changes made up to that point are backed out. Consistency ensures that all integrity conditions in the database be maintained with each transaction. Isolation ensures that each transaction is isolated from other transactions; hence, each transaction only accesses data that are part of a consistent database state. Durability ensures that, when a transaction has been reported back to a user as complete, the resultant changes to the database will survive subsequent hardware or software failures.

QUESTION 267

Which of the following would help to ensure the portability of an application connected to a database?

- A. Verification of database import and export procedures
- B. Usage of a structured query language (SQL)
- C. Analysis of stored procedures/triggers
- D. Synchronization of the entity-relation model with the database physical schema

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The use of SQL facilitates portability. Verification of import and export procedures with other systems ensures better interfacing with other systems, analyzing stored procedures/triggers ensures proper access/ performance, and reviewing the design entity- relation model will be helpful, but none of these contribute to the portability of an application connecting to a database.

QUESTION 268

Business units are concerned about the performance of a newly implemented system. Which of the following should an IS auditor recommend?

- A. Develop a baseline and monitor system usage.
- B. Define alternate processing procedures.
- C. Prepare the maintenance manual.
- D. Implement the changes users have suggested.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor should recommend the development of a performance baseline and monitor the system's performance, against the baseline, to develop empirical data upon which decisions for modifying the system can be made. Alternate processing procedures and a maintenance manual will not alter a system's performance. Implementing changes without knowledge of the cause(s) for the perceived poor performance may not result in a more efficient system.

QUESTION 269

A company undertakes a business process reengineering (BPR) project in support of a new and direct marketing approach to its customers. Which of the following would be an IS auditor's main concern about the

new process?

- A. Whether key controls are in place to protect assets and information resources
- B. If the system addresses corporate customer requirements
- C. Whether the system can meet the performance goals (time and resources)
- D. Whether owners have been identified who will be responsible for the process

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The audit team must advocate the inclusion of the key controls and verify that the controls are in place before implementing the new process. Choices B, C and D are objectives that the business process reengineering (BPR) process should achieve, but they are not the auditor's primary concern.

QUESTION 270

A company has implemented a new client-server enterprise resource planning (ERP) system. Local branches transmit customer orders to a central manufacturing facility. Which of the following would BEST ensure that the orders are entered accurately and the corresponding products are produced?

- A. Verifying production to customer orders
- B. Logging all customer orders in the ERP system
- C. Using hash totals in the order transmitting process
- D. Approving (production supervisor) orders prior to production

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Verification will ensure that production orders match customer orders. Logging can be used to detect inaccuracies, but does not in itself guarantee accurate processing. Hash totals will ensure accurate order transmission, but not accurate processing centrally. Production supervisory approval is a time consuming, manual process that does not guarantee proper control.

QUESTION 271

When two or more systems are integrated, input/output controls must be reviewed by an IS auditor in the:

- A. systems receiving the output of other systems.
- B. systems sending output to other systems.
- C. systems sending and receiving data.
- D. interfaces between the two systems.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Both of the systems must be reviewed for input/output controls, since the output for one system is the input for the other.

QUESTION 272

An IS auditor who has discovered unauthorized transactions during a review of EDI transactions is likely to recommend improving the:

- A. EDI trading partner agreements.
- B. physical controls for terminals.
- C. authentication techniques for sending and receiving messages.
- D. program change control procedures.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Authentication techniques for sending and receiving messages play a key role in minimizing exposure to unauthorized transactions. The EDI trading partner agreements would minimize exposure to legal issues.

QUESTION 273

An IS auditor recommends that an initial validation control be programmed into a credit card transaction capture application. The initial validation process would MOST likely:

- A. check to ensure that the type of transaction is valid for the card type.
- B. verify the format of the number entered then locate it on the database.
- C. ensure that the transaction entered is within the cardholder's credit limit.
- D. confirm that the card is not shown as lost or stolen on the master file.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The initial validation should confirm whether the card is valid. This validity is established through the card number and PIN entered by the user. Based on this initial validation, all other validations will proceed. A validation control in data capture will ensure that the data entered is valid (i.e., it can be processed by the system). If the data captured in the initial validation is not valid (if the card number or PIN do not match with the database), then the card will be rejected or captured per the controls in place. Once initial validation is completed, then other validations specific to the card and cardholder would be performed.

QUESTION 274

A company has recently upgraded its purchase system to incorporate EDI transmissions. Which of the following controls should be implemented in the EDI interface to provide for efficient data mapping?

- A. Key verification
- B. One-for-one checking
- C. Manual recalculations
- D. Functional acknowledgements

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Acting as an audit trail for EDI transactions, functional acknowledgements are one of the main controls used in data mapping. All the other choices are manual input controls, whereas data mapping deals with automatic

integration of data in the receiving company.

QUESTION 275

Once an organization has finished the business process reengineering (BPR) of all its critical operations, an IS auditor would MOST likely focus on a review of:

- A. pre-BPR process flowcharts.
- B. post-BPR process flowcharts.
- C. BPR project plans.
- D. continuous improvement and monitoring plans.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor's task is to identify and ensure that key controls have been incorporated into the reengineered process. Choice A is incorrect because an IS auditor must review the process as it is today, not as it was in the past. Choices C and D are incorrect because they are steps within a BPR project.

QUESTION 276

A company uses a bank to process its weekly payroll. Time sheets and payroll adjustment forms (e.g., hourly rate changes, terminations) are completed and delivered to the bank, which prepares checks (cheques) and reports for distribution. To BEST ensure payroll data accuracy:

- A. payroll reports should be compared to input forms.
- B. gross payroll should be recalculated manually.
- C. checks (cheques) should be compared to input forms.
- D. checks (cheques) should be reconciled with output reports.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The best way to confirm data accuracy, when input is provided by the company and output is generated by the bank, is to verify the data input (input forms) with the results of the payroll reports. Hence, comparing payroll reports with input forms is the best mechanism of verifying data accuracy. Recalculating gross payroll manually would only verify whether the processing is correct and not the data accuracy of inputs. Comparing checks (cheques) to input forms is not feasible as checks (cheques) have the processed information and input forms have the input data. Reconciling checks (cheques) with output reports only confirms that checks (cheques) have been issued as per output reports.

QUESTION 277

Which of the following represents the GREATEST potential risk in an EDI environment?

- A. Transaction authorization
- B. Loss or duplication of EDI transmissions
- C. Transmission delay
- D. Deletion or manipulation of transactions prior to or after establishment of application controls

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Since the interaction between parties is electronic, there is no inherent authentication occurring; therefore, transaction authorization is the greatest risk. Choices B and D are examples of risks, but the impact is not as great as that of unauthorized transactions. Transmission delays may terminate the process or hold the line until the normal time for processing has elapsed; however, there will be no loss of data.

QUESTION 278

Which of the following is the MOST critical and contributes the greatest to the quality of data in a data warehouse?

- A. Accuracy of the source data
- B. Credibility of the data source
- C. Accuracy of the extraction process
- D. Accuracy of the data transformation

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Accuracy of source data is a prerequisite for the quality of the data in a data warehouse. Credibility of the data source, accurate extraction processes and accurate transformation routines are all important, but would not change inaccurate data into quality (accurate) data.

QUESTION 279

When transmitting a payment instruction, which of the following will help verify that the instruction was not duplicated?

- A. Use of a cryptographic hashing algorithm
- B. Enciphering the message digest
- C. Deciphering the message digest
- D. A sequence number and time stamp

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When transmitting data, a sequence number and/or time stamp built into the message to make it unique can be checked by the recipient to ensure that the message was not intercepted and replayed. This is known as replay protection, and could be used to verify that a payment instruction was not duplicated. Use of a cryptographic hashing algorithm against the entire message helps achieve data integrity. Enciphering the message digest using the sender's private key, which signs the sender's digital signature to the document, helps in authenticating the transaction. When the message is deciphered by the receiver using the sender's public key, it ensures that the message could only have come from the sender. This process of sender authentication achieves nonrepudiation.

QUESTION 280

When reviewing input controls, an IS auditor observes that, in accordance with corporate policy, procedures allow supervisory override of data validation edits. The IS auditor should:

- A. not be concerned since there may be other compensating controls to mitigate the risks.
- B. ensure that overrides are automatically logged and subject to review.
- C. verify whether all such overrides are referred to senior management for approval.
- D. recommend that overrides not be permitted.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

If input procedures allow overrides of data validation and editing, automatic logging should occur. A management individual who did not initiate the override should review this log. An IS auditor should not assume that compensating controls exist. As long as the overrides are policy- compliant, there is no need for senior management approval or a blanket prohibition.

QUESTION 281

When using an integrated test facility (ITF), an IS auditor should ensure that:

- A. production data are used for testing.
- B. test data are isolated from production data.
- C. a test data generator is used.
- D. master files are updated with the test data.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An integrated test facility (ITF) creates a fictitious file in the database, allowing for test transactions to be processed simultaneously with live data. While this ensures that periodic testing does not require a separate test process, there is a need to isolate test data from production data. An IS auditor is not required to use production data or a test data generator. Production master files should not be updated with test data.

QUESTION 282

A clerk changed the interest rate for a loan on a master file. The rate entered is outside the normal range for such a loan. Which of the following controls is MOST effective in providing reasonable assurance that the change was authorized?

- A. The system will not process the change until the clerk's manager confirms the change by entering an approval code.
- B. The system generates a weekly report listing all rate exceptions and the report is reviewed by the clerk's manager.
- C. The system requires the clerk to enter an approval code.
- D. The system displays a warning message to the clerk.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Choice A would prevent or detect the use of an unauthorized interest rate. Choice B informs the manager after the fact that a change was made, thereby making it possible for transactions to use an unauthorized rate prior to management review. Choices C and D do not prevent the clerk from entering an unauthorized rate change.

QUESTION 283

The GREATEST advantage of using web services for the exchange of information between two systems is:

- A. secure communications.
- B. improved performance.
- C. efficient interfacing.
- D. enhanced documentation.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Web services facilitate the exchange of information between two systems, regardless of the operating system or programming language used. Communication is not necessarily securer or faster, and there is no documentation benefit in using web services.

QUESTION 284

An IS auditor reviewing an accounts payable system discovers that audit logs are not being reviewed. When this issue is raised with management the response is that additional controls are not necessary because effective system access controls are in place. The BEST response the auditor can make is to:

- A. review the integrity of system access controls.
- B. accept management's statement that effective access controls are in place.
- C. stress the importance of having a system control framework in place.
- D. review the background checks of the accounts payable staff.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Experience has demonstrated that reliance purely on preventative controls is dangerous. Preventative controls may not prove to be as strong as anticipated or their effectiveness can deteriorate over time. Evaluating the cost of controls versus the quantum of risk is a valid management concern. However, in a high-risk system a comprehensive control framework is needed, intelligent design should permit additional detective and corrective controls to be established that don't have high ongoing costs, e.g., automated interrogation of logs to highlight suspicious individual transactions or data patterns. Effective access controls are, in themselves, a positive but, for reasons outlined above, may not sufficiently compensate for other control weaknesses. In this situation the IS auditor needs to be proactive. The IS auditor has a fundamental obligation to point out control weaknesses that give rise to unacceptable risks to the organization and work with management to have these corrected. Reviewing background checks on accounts payable staff does not provide evidence that fraud will not occur.

QUESTION 285

When evaluating the controls of an EDI application, an IS auditor should PRIMARILY be concerned with the risk of:

- A. excessive transaction turnaround time.
- B. application interface failure.
- C. improper transaction authorization.
- D. no validated batch totals.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Foremost among the risks associated with electronic data interchange (EDI) is improper transaction authorization. Since the interaction with the parties is electronic, there is no inherent authentication. The other choices, although risks, are not as significant.

QUESTION 286

When reviewing an organization's approved software product list, which of the following is the MOST important thing to verify?

- A. The risks associated with the use of the products are periodically assessed
- B. The latest version of software is listed for each product
- C. Due to licensing issues the list does not contain open source software
- D. After hours' support is offered

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Since the business conditions surrounding vendors may change, it is important for an organization to conduct periodic risk assessments of the vendor software list. This might be best incorporated into the IT risk management process. Choices B, C and D are possible considerations but would not be the most important.

QUESTION 287

An existing system is being extensively enhanced by extracting and reusing design and program components.

This is an example of:

- A. reverse engineering.
- B. prototyping.
- C. software reuse.
- D. reengineering.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Old (legacy) systems that have been corrected, adapted and enhanced extensively require reengineering to remain maintainable. Reengineering is a rebuilding activity to incorporate new technologies into existing systems. Using program language statements, reverse engineering involves reversing a program's machine code into the source code in which it was written to identify malicious content in a program, such as a virus, or to adapt a program written for use with one processor for use with a differently designed processor. Prototyping is the development of a system through controlled trial and error. Software reuse is the process of planning, analyzing and using previously developed software components. The reusable components are integrated into the current software product systematically.

QUESTION 288

An IS auditor performing an application maintenance audit would review the log of program changes for the:

- A. authorization of program changes.
- B. creation date of a current object module.
- C. number of program changes actually made.
- D. creation date of a current source program.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The manual log will most likely contain information on authorized changes to a program. Deliberate, unauthorized changes will not be documented by the responsible party. An automated log, found usually in library management products, and not a changelog would most likely contain date information for the source and executable modules.

QUESTION 289

After discovering a security vulnerability in a third-party application that interfaces with several external systems, a patch is applied to a significant number of modules. Which of the following tests should an IS auditor recommend?

- A. Stress
- B. Black box
- C. Interface
- D. System

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Given the extensiveness of the patch and its interfaces to external systems, system testing is most appropriate. Interface testing is not enough, and stress or black box testing are inadequate in these circumstances.

QUESTION 290

When performing an audit of a client relationship management (CRM) system migration project, which of the following should be of GREATEST concern to an IS auditor?

- A. The technical migration is planned for a Friday preceding a long weekend, and the time window is too short for completing all tasks.
- B. Employees pilot-testing the system are concerned that the data representation in the new system is completely different from the old system.
- C. A single implementation is planned, immediately decommissioning the legacy system.
- D. Five weeks prior to the target date, there are still numerous defects in the printing functionality of the new system's software.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Major system migrations should include a phase of parallel operation or a phased cut-over to reduce implementation risks. Decommissioning or disposing of the old hardware would complicate any fallback strategy, should the new system not operate correctly. A weekend can be used as a time buffer so that the

new system will have a better chance of being up and running after the weekend. A different data representation does not mean different data presentation at the front end. Even when this is the case, this issue can be solved by adequate training and user support. The printing functionality is commonly one of the last functions to be tested in a new system because it is usually the last step performed in any business event. Thus, meaningful testing and the respective error fixing are only possible after all other parts of the software have been successfully tested.

QUESTION 291

Which of the following reports should an IS auditor use to check compliance with a service level agreements (SLA) requirement for uptime?

- A. Utilization reports
- B. Hardware error reports
- C. System logs
- D. Availability reports

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

IS inactivity, such as downtime, is addressed by availability reports. These reports provide the time periods during which the computer was available for utilization by users or other processes. Utilization reports document the use of computer equipment, and can be used by management to predict how/where/when resources are required. Hardware error reports provide information to aid in detecting hardware failures and initiating corrective action. System logs are a recording of the

system's activities.

QUESTION 292

A benefit of quality of service (QoS) is that the:

- A. entire network's availability and performance will be significantly improved.
- B. telecom carrier will provide the company with accurate service-level compliance reports.
- C. participating applications will have guaranteed service levels.
- D. communications link will be supported by security controls to perform secure online transactions.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The main function of QoS is to optimize network performance by assigning priority to business applications and end users, through the allocation of dedicated parts of the bandwidth to specific traffic. Choice A is not true because the communication itself will not be improved. While the speed of data exchange for specific applications could be faster, availability will not be improved. The QoS tools that many carriers are using do not provide reports of service levels; however, there are other tools that will generate service-level reports. Even when QoS is integrated with firewalls, VPNs, encryption tools and others, the tool itself is not intended to provide security controls.

QUESTION 293

An organization has outsourced its help desk. Which of the following indicators would be the best to include in the SLA?

- A. Overall number of users supported
- B. Percentage of incidents solved in the first call
- C. Number of incidents reported to the help desk
- D. Number of agents answering the phones

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Since it is about service level (performance) indicators, the percentage of incidents solved on the first call is the only option that is relevant. Choices A, C and D are not quality measures of the help desk service.

QUESTION 294

The PRIMARY objective of service-level management (SLM) is to:

- A. define, agree, record and manage the required levels of service.
- B. ensure that services are managed to deliver the highest achievable level of availability.
- C. keep the costs associated with any service at a minimum.
- D. monitor and report any legal noncompliance to business management.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The objective of service-level management (SLM) is to negotiate, document and manage (i.e., provide and monitor) the services in the manner in which the customer requires those services. This does not necessarily ensure that services are delivered at the highest achievable level of availability (e.g., redundancy and clustering). Although maximizing availability might be necessary for some critical services, it cannot be applied as a general rule of thumb. SLM cannot ensure that costs for all services will be kept at a low or minimum level, since costs associated with a service will directly reflect the customer's requirements. Monitoring and reporting legal noncompliance is not a part of SLM.

QUESTION 295

Which of the following should be of PRIMARY concern to an IS auditor reviewing the management of external IT service providers?

- A. Minimizing costs for the services provided
- B. Prohibiting the provider from subcontracting services
- C. Evaluating the process for transferring knowledge to the IT department
- D. Determining if the services were provided as contracted

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

From an IS auditor's perspective, the primary objective of auditing the management of service providers should be to determine if the services that were requested were provided in a way that is acceptable, seamless and in line with contractual agreements. Minimizing costs, if applicable and achievable (depending on the customer's need) is traditionally not part of an IS auditor's job. This would normally be done by a line management function within the IT department. Furthermore, during an audit, it is too late to minimize the costs for existing provider arrangements. Subcontracting providers could be a concern, but it would not be the primary concern. Transferring knowledge to the internal IT department might be desirable under certain circumstances, but should not be the primary

concern of an IS auditor when auditing IT service providers and the management thereof.

QUESTION 296

IT best practices for the availability and continuity of IT services should:

- A. minimize costs associated with disaster-resilient components.
- B. provide for sufficient capacity to meet the agreed upon demands of the business.
- C. provide reasonable assurance that agreed upon obligations to customers can be met.
- D. produce timely performance metric reports.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is important that negotiated and agreed commitments (i.e., service level agreements [SLAs]) can be fulfilled all the time. If this were not achievable, IT should not have agreed to these requirements, as entering into such a commitment would be misleading to the business. 'All the time' in this context directly relates to the 'agreed obligations' and does not imply that a service has to be available 100 percent of the time. Costs are a result of availability and service continuity management and may only be partially controllable. These costs directly reflect the agreed upon obligations. Capacity management is a necessary, but not sufficient, condition of availability.

Despite the possibility that a lack of capacity may result in an availability issue, providing the capacity necessary for seamless operations of services would be done within capacity management, and not within availability management. Generating reports might be a task of availability and service continuity management, but that is true for many other areas of interest as well (e.g., incident, problem, capacity and change management).

QUESTION 297

During a human resources (HR) audit, an IS auditor is informed that there is a verbal agreement between the IT and HR departments as to the level of IT services expected. In this situation, what should the IS auditor do FIRST?

- A. Postpone the audit until the agreement is documented
- B. Report the existence of the undocumented agreement to senior management
- C. Confirm the content of the agreement with both departments
- D. Draft a service level agreement (SLA) for the two departments

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor should first confirm and understand the current practice before making any recommendations. The agreement can be documented after it has been established that there is an agreement in place. The fact that there is not a written agreement does not justify postponing the audit, and reporting to senior management is not necessary at this stage of the audit. Drafting a service level agreement (SLA) is not the IS auditor's responsibility.

QUESTION 298

Which of the following procedures would MOST effectively detect the loading of illegal software packages onto a network?

- A. The use of diskless workstations
- B. Periodic checking of hard drives
- C. The use of current antivirus software
- D. policies that result in instant dismissal if violated

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The periodic checking of hard drives would be the most effective method of identifying illegal software packages loaded to the network. Antivirus software will not necessarily identify illegal software, unless the software contains a virus. Diskless workstations act as a preventive control and are not effective, since users could still download software from other than diskless workstations. Policies lay out the rules about loading the software, but will not detect the actual occurrence.

QUESTION 299

To determine which users can gain access to the privileged supervisory state, which of the following should an IS auditor review?

- A. System access log files
- B. Enabled access control software parameters
- C. Logs of access control violations
- D. System configuration files for control options used

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A review of system configuration files for control options used would show which users have access to the privileged supervisory state. Both systems access log files and logs of access violations are detective in nature. Access control software is run under the operating system.

QUESTION 300

Which of the following would an IS auditor consider to be the MOST helpful when evaluating the effectiveness and adequacy of a computer preventive maintenance program?

- A. A system downtime log
- B. Vendors' reliability figures
- C. Regularly scheduled maintenance log
- D. A written preventive maintenance schedule

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A system downtime log provides information regarding the effectiveness and adequacy of computer preventive maintenance programs.

QUESTION 301

Which of the following exposures associated with the spooling of sensitive reports for offline printing should an IS auditor consider to be the MOST serious?

- A. Sensitive data can be read by operators.
- B. Data can be amended without authorization.
- C. Unauthorized report copies can be printed.
- D. Output can be lost in the event of system failure.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Unless controlled, spooling for offline printing may enable additional copies to be printed. Print files are unlikely to be available for online reading by operations. Data on spool files are no easier to amend without authority than any other file. There is usually a lesser threat of unauthorized access to sensitive reports in the event of a system failure.

QUESTION 302

Applying a retention date on a file will ensure that:

- A. data cannot be read until the date is set.
- B. data will not be deleted before that date.
- C. backup copies are not retained after that date.
- D. datasets having the same name are differentiated.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A retention date will ensure that a file cannot be overwritten before that date has passed. The retention date will not affect the ability to read the file. Backup copies would be expected to have a different retention date and therefore may be retained after the file has been overwritten. The creation date, not the retention date, will differentiate files with the same name.

QUESTION 303

Which of the following is a network diagnostic tool that monitors and records network information?

- A. Online monitor
- B. Downtime report
- C. Help desk report
- D. Protocol analyzer

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Protocol analyzers are network diagnostic tools that monitor and record network information from packets traveling in the link to which the analyzer is attached. Online monitors (choice A) measure telecommunications transmissions and determine whether transmissions were accurate and complete. Downtime reports (choice B) track the availability of telecommunication lines and circuits. Help desk reports (choice C) are prepared by the help desk, which is staffed or supported by IS technical support personnel trained to handle problems occurring during the course of IS operations.

QUESTION 304

An intruder accesses an application server and makes changes to the system log. Which of the following would enable the identification of the changes?

- A. Mirroring the system log on another server
- B. Simultaneously duplicating the system log on a write-once disk
- C. Write-protecting the directory containing the system log
- D. Storing the backup of the system log offsite

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A write-once CD cannot be overwritten. Therefore, the system log duplicated on the disk could be compared to the original log to detect differences, which could be the result of changes made by an intruder. Write-protecting the system log does not prevent deletion or modification, since the superuser can override the write protection. Backup and mirroring may overwrite earlier files and may not be current.

QUESTION 305

IT operations for a large organization have been outsourced. An IS auditor reviewing the outsourced operation should be MOST concerned about which of the following findings?

- A. The outsourcing contract does not cover disaster recovery for the outsourced IT operations.
- B. The service provider does not have incident handling procedures.
- C. Recently a corrupted database could not be recovered because of library management problems.
- D. Incident logs are not being reviewed.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The lack of a disaster recovery provision presents a major business risk. Incorporating such a provision into the contract will provide the outsourcing organization leverage over the service provider. Choices B, C and D are problems that should be addressed by the service provider, but are not as important as contract requirements for disaster recovery.

QUESTION 306

Which of the following BEST ensures the integrity of a server's operating system?

- A. Protecting the server in a secure location
- B. Setting a boot password
- C. Hardening the server configuration
- D. Implementing activity logging

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Hardening a system means to configure it in the most secure manner (install latest security patches, properly

define the access authorization for users and administrators, disable insecure options and uninstall unused services) to prevent nonprivileged users from gaining the right to execute privileged instructions and thus take control of the entire machine, jeopardizing the OS's integrity. Protecting the server in a secure location and setting a boot password are good practices, but do not ensure that a user will not try to exploit logical vulnerabilities and compromise the OS. Activity logging has two weaknesses in this scenario-it is a detective control (not a preventive one), and the attacker who already gained privileged access can modify logs or disable them.

QUESTION 307

The MOST significant security concerns when using flash memory (e.g., USB removable disk) is that the:

- A. contents are highly volatile.
- B. data cannot be backed up.
- C. data can be copied.
- D. device may not be compatible with other peripherals.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: Unless properly controlled, flash memory provides an avenue for anyone to copy any content with ease. The contents stored in flash memory are not volatile. Backing up flash memory data is not a control concern, as the data are sometimes stored as a backup. Flash memory will be accessed through a PC rather than any other peripheral; therefore, compatibility is not an issue.

QUESTION 308

The database administrator (DBA) suggests that DB efficiency can be improved by denormalizing some tables.

This would result in:

- A. loss of confidentiality.
- B. increased redundancy.
- C. unauthorized accesses.
- D. application malfunctions.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Normalization is a design or optimization process for a relational database (DB) that minimizes redundancy; therefore, denormalization would increase redundancy. Redundancy which is usually considered positive when it is a question of resource availability is negative in a database environment, since it demands additional and otherwise unnecessary data handling efforts.

Denormalization is sometimes advisable for functional reasons. It should not cause loss of confidentiality, unauthorized accesses or application malfunctions.

QUESTION 309

Web and e-mail filtering tools are PRIMARILY valuable to an organization because they:

- A. protect the organization from viruses and nonbusiness materials.
- B. maximize employee performance.
- C. safeguard the organization's image.
- D. assist the organization in preventing legal issues

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The main reason for investing in web and e-mail filtering tools is that they significantly reduce risks related to viruses, spam, mail chains, recreational surfing and recreational e-mail. Choice B could be true in some circumstances (i.e., it would need to be implemented along with an awareness program, so that employee performance can be significantly improved). However, in such cases, it would not be as relevant as choice A.

Choices C and D are secondary or indirect benefits.

QUESTION 310

The BEST way to minimize the risk of communication failures in an e-commerce environment would be to use:

- A. compression software to minimize transmission duration.
- B. functional or message acknowledgments.
- C. a packet-filtering firewall to reroute messages.
- D. leased asynchronous transfer mode lines.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Leased asynchronous transfer mode lines are a way to avoid using public and shared infrastructures from the carrier or Internet service provider that have a greater number of communication failures. Choice A, compression software, is a valid way to reduce the problem, but is not as good as leased asynchronous transfer mode lines. Choice B is a control based on higher protocol layers and helps if communication lines are introducing noise, but not if a link is down. Choice C, a packet-filtering firewall, does not reroute messages.

QUESTION 311

An IS auditor reviewing an organization's data file control procedures finds that transactions are applied to the most current files, while restart procedures use earlier versions. The IS auditor should recommend the implementation of:

- A. source documentation retention.
- B. data file security.
- C. version usage control.
- D. one-for-one checking.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

For processing to be correct, it is essential that the proper version of a file is used. Transactions should be applied to the most current database, while restart procedures should use earlier versions. Source documentation should be retained for an adequate time period to enable documentation retrieval, reconstruction or verification of data, but it does not aid in ensuring that the correct version of a file will be used. Data file security controls prevent access by unauthorized users who could then alter the data files; however, it does not ensure that the correct file will be used. It is necessary to ensure that all documents have been received for processing, one-for-one; however, this does not ensure the use of the correct file.

QUESTION 312

Which of the following BEST limits the impact of server failures in a distributed environment?

- A. Redundant pathways
- B. Clustering
- C. Dial backup lines
- D. Standby power

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Clustering allows two or more servers to work as a unit, so that when one of them fails, the other takes over. Choices A and C are intended to minimize the impact of channel communications failures, but not a server failure. Choice D provides an alternative power source in the event of an energy failure.

QUESTION 313

When reviewing a hardware maintenance program, an IS auditor should assess whether:

- A. the schedule of all unplanned maintenance is maintained.
- B. it is in line with historical trends.
- C. it has been approved by the IS steering committee.
- D. the program is validated against vendor specifications.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Though maintenance requirements vary based on complexity and performance workloads, a hardware maintenance schedule should be validated against the vendor-provided specifications. For business reasons, an organization may choose a more aggressive maintenance program than the vendor's program. The maintenance program should include maintenance performance history, be it planned, unplanned, executed or exceptional. Unplanned maintenance cannot be scheduled. Hardware maintenance programs do not necessarily need to be in line with historical trends. Maintenance schedules normally are not approved by the steering committee.

QUESTION 314

An IS auditor observes a weakness in the tape management system at a data center in that some parameters are set to bypass or ignore tape header records. Which of the following is the MOST effective compensating control for this weakness?

- A. Staging and job set up
- B. Supervisory review of logs
- C. Regular back-up of tapes
- D. Offsite storage of tapes

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If the IS auditor finds that there are effective staging and job set up processes, this can be accepted as a

compensating control. Choice B is a detective control while choices C and D are corrective controls, none of which would serve as good compensating controls.

QUESTION 315

To verify that the correct version of a data file was used for a production run, an IS auditor should review:

- A. operator problem reports.
- B. operator work schedules.
- C. system logs.
- D. output distribution reports.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

System logs are automated reports which identify most of the activities performed on the computer. Programs that analyze the system log have been developed to report on specifically defined items. The auditor can then carry out tests to ensure that the correct file version was used for a production run. Operator problem reports are used by operators to log computer operation problems. Operator work schedules are maintained to assist in human resources planning. Output distribution reports identify all application reports generated and their distribution.

QUESTION 316

Which of the following is the BEST type of program for an organization to implement to aggregate, correlate and store different log and event files, and then produce weekly and monthly reports for IS auditors?

- A. A security information event management (SIEM) product
- B. An open-source correlation engine
- C. A log management tool
- D. An extract, transform, load (ETL) system

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A log management tool is a product designed to aggregate events from many log files (with distinct formats and from different sources), store them and typically correlate them offline to produce many reports (e.g., exception reports showing different statistics including anomalies and suspicious activities), and to answer time-based queries (e.g., how many users have entered the system between 2 a.m. and 4 a.m. over the past three weeks?). A SIEM product has some similar features. It correlates events from log files, but does it online and normally is not oriented to storing many weeks of historical information and producing audit reports. A correlation engine is part of a SIEM product. It is oriented to making an online correlation of events. An extract, transform, load (ETL) is part of a business intelligence system, dedicated to extracting operational or production data, transforming that data and loading them to a central repository (data warehouse or data mart); an ETL does not correlate data or produce reports, and normally it does not have extractors to read log file formats.

QUESTION 317

Doing which of the following during peak production hours could result in unexpected downtime?

- A. Performing data migration or tape backup
- B. Performing preventive maintenance on electrical systems
- C. Promoting applications from development to the staging environment
- D. Replacing a failed power supply in the core router of the data center

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Choices A and C are processing events which may impact performance, but would not cause downtime. Enterprise-class routers have redundant hot-swappable power supplies, so replacing a failed power supply should not be an issue. Preventive maintenance activities should be scheduled for non-peak times of the day, and preferably during a maintenance window time period. A mishap or incident caused by a maintenance worker could result in unplanned downtime.

QUESTION 318

Which of the following would BEST maintain the integrity of a firewall log?

- A. Granting access to log information only to administrators
- B. Capturing log events in the operating system layer
- C. Writing dual logs onto separate storage media
- D. Sending log information to a dedicated third-party log server

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Establishing a dedicated third-party log server and logging events in it is the best procedure for maintaining the integrity of a firewall log. When access control to the log server is adequately maintained, the risk of unauthorized log modification will be mitigated, therefore improving the integrity of log information. To enforce segregation of duties, administrators should not have access to log files. This primarily contributes to the assurance of confidentiality rather than integrity. There are many ways to capture log information: through the application layer, network layer, operating systems layer, etc.; however, there is no log integrity advantage in capturing events in the operating systems layer. If it is a highly mission-critical information system, it may be nice to run the system with a dual log mode. Having logs in two different storage devices will primarily contribute to the assurance of the availability of log information, rather than to maintaining its integrity.

QUESTION 319

Which of the following will prevent dangling tuples in a database?

- A. Cyclic integrity
- B. Domain integrity
- C. Relational integrity
- D. Referential integrity

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Referential integrity ensures that a foreign key in one table will equal null or the value of a primary in the other table. For every tuple in a table having a referenced/foreign key, there should be a corresponding tuple in another table, i.e., for existence of all foreign keys in the original tables, if this condition is not satisfied, then it results in a dangling tuple. Cyclical checking is the control technique for the regular checking of accumulated

data on a file against authorized source documentation. There is no cyclical integrity testing. Domain integrity testing ensures that a data item has a legitimate value in the correct range or set. Relational integrity is performed at the record level and is ensured by calculating and verifying specific fields.

QUESTION 320

The objective of concurrency control in a database system is to:

- A. restrict updating of the database to authorized users.
- B. prevent integrity problems when two processes attempt to update the same data at the same time.
- C. prevent inadvertent or unauthorized disclosure of data in the database.
- D. ensure the accuracy, completeness and consistency of data.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Concurrency controls prevent data integrity problems, which can arise when two update processes access the same data item at the same time. Access controls restrict updating of the database to authorized users, and controls such as passwords prevent the inadvertent or unauthorized disclosure of data from the database. Quality controls, such as edits, ensure the accuracy, completeness and consistency of data maintained in the database.

QUESTION 321

Which of the following controls would provide the GREATEST assurance of database integrity?

- A. Audit log procedures
- B. Table link/reference checks
- C. Query/table access time checks
- D. Rollback and roll forward database features

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Performing table link/reference checks serves to detect table linking errors (such as completeness and accuracy of the contents of the database), and thus provides the greatest assurance of database integrity. Audit log procedures enable recording of all events that have been identified and help in tracing the events. However, they only point to the event and do not ensure completeness or accuracy of the database's contents. Querying/monitoring table access time checks helps designers improve database performance, but not integrity. Rollback and roll forward database features ensure recovery from an abnormal disruption. They assure the integrity of the transaction that was being processed at the time of disruption, but do not provide assurance on the integrity of the contents of the database.

QUESTION 322

An IS auditor analyzing the audit log of a database management system (DBMS) finds that some transactions were partially executed as a result of an error, and are not rolled back. Which of the following transaction processing features has been violated?

- A. Consistency
- B. Isolation
- C. Durability
- D. Atomicity

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Atomicity guarantees that either the entire transaction is processed or none of it is. Consistency ensures that the database is in a legal state when the transaction begins and ends, isolation means that, while in an intermediate state, the transaction data is invisible to external operations. Durability guarantees that a successful transaction will persist, and cannot be undone.

QUESTION 323

During maintenance of a relational database, several values of the foreign key in a transaction table of a relational database have been corrupted. The consequence is that:

- A. the detail of involved transactions may no longer be associated with master data, causing errors when these transactions are processed.
- B. there is no way of reconstructing the lost information, except by deleting the dangling tuples and reentering the transactions.
- C. the database will immediately stop execution and lose more information.
- D. the database will no longer accept input data.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When the external key of a transaction is corrupted or lost, the application system will normally be incapable of directly attaching the master data to the transaction data. This will normally cause the system to undertake a sequential search and slow down the processing. If the concerned files are big, this slowdown will be unacceptable. Choice B is incorrect, since a system can recover the corrupted external key by reindexing the table. Choices C and D would not result from a corrupted foreign key.

QUESTION 324

In a relational database with referential integrity, the use of which of the following keys would prevent deletion of a row from a customer table as long as the customer number of that row is stored with live orders on the orders table?

- A. Foreign key
- B. Primary key
- C. Secondary key
- D. Public key

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In a relational database with referential integrity, the use of foreign keys would prevent events such as primary key changes and record deletions, resulting in orphaned relations within the database. It should not be possible to delete a row from a customer table when the customer number (primary key) of that row is stored with live orders on the orders table (the foreign key to the customer table). A primary key works in one table, so it is not able to provide/ensure referential integrity by itself. Secondary keys that are not foreign keys are not subject to referential integrity checks. Public key is related to encryption and not linked in any way to referential

integrity.

QUESTION 325

When performing a database review, an IS auditor notices that some tables in the database are not normalized. The IS auditor should next:

- A. recommend that the database be normalized.
- B. review the conceptual data model.
- C. review the stored procedures.
- D. review the justification.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If the database is not normalized, the IS auditor should review the justification since, in some situations, denormalization is recommended for performance reasons. The IS auditor should not recommend normalizing the database until further investigation takes place. Reviewing the conceptual data model or the stored procedures will not provide information about normalization.

QUESTION 326

A database administrator has detected a performance problem with some tables which could be solved through denormalization. This situation will increase the risk of:

- A. concurrent access.
- B. deadlocks.
- C. unauthorized access to data.
- D. a loss of data integrity.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Normalization is the removal of redundant data elements from the database structure. Disabling normalization in relational databases will create redundancy and a risk of not maintaining consistency of data, with the consequent loss of data integrity. Deadlocks are not caused by denormalization. Access to data is controlled by defining user rights to information, and is not affected by denormalization.

QUESTION 327

An IS auditor finds that client requests were processed multiple times when received from different independent departmental databases, which are synchronized weekly. What would be the BEST recommendation?

- A. increase the frequency for data replication between the different department systems to ensure timely updates.
- B. Centralize all request processing in one department to avoid parallel processing of the same request.
- C. Change the application architecture so that common data is held in just one shared database for all departments.
- D. implement reconciliation controls to detect duplicates before orders are processed in the systems.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Keeping the data in one place is the best way to ensure that data are stored without redundancy and that all users have the same data on their systems. Although increasing the frequency may help to minimize the problem, the risk of duplication cannot be eliminated completely because parallel data entry is still possible. Business requirements will most likely dictate where data processing activities are performed. Changing the business structure to solve an IT problem is not practical or politically feasible. Detective controls do not solve the problem of duplicate processing, and would require that an additional process be implemented to handle the discovered duplicates.

QUESTION 328

Which of the following database controls would ensure that the integrity of transactions is maintained in an online transaction processing system's database?

- A. Authentication controls
- B. Data normalization controls
- C. Read/write access log controls
- D. Commitment and rollback controls

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Commitment and rollback controls are directly relevant to integrity. These controls ensure that database operations that form a logical transaction unit will complete in its entirety or not at all; i.e., if, for some reason, a transaction cannot be fully completed, then incomplete inserts/updates/deletes are rolled back so that the database returns to its pretransaction state. All other choices would not address transaction integrity.

QUESTION 329

An IS auditor finds that, at certain times of the day, the data warehouse query performance decreases significantly. Which of the following controls would it be relevant for the IS auditor to review?

- A. Permanent table-space allocation
- B. Commitment and rollback controls
- C. User spool and database limit controls
- D. Read/write access log controls

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

User spool limits restrict the space available for running user queries. This prevents poorly formed queries from consuming excessive system resources and impacting general query performance. Limiting the space available to users in their own databases prevents them from building excessively large tables. This helps to control space utilization which itself acts to help performance by maintaining a buffer between the actual data volume stored and the physical device capacity. Additionally, it prevents users from consuming excessive resources in ad hoc table builds (as opposed to scheduled production loads that often can run overnight and are optimized for performance purposes), in a data warehouse, since you are not running online transactions, commitment and rollback does not have an impact on performance. The other choices are not as likely to be the root cause of this performance issue.

QUESTION 330

Which of the following is widely accepted as one of the critical components in networking management?

- A. Configuration management
- B. Topological mappings
- C. Application of monitoring tools
- D. Proxy server troubleshooting

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Configuration management is widely accepted as one of the key components of any network, since it establishes how the network will function internally and externally, it also deals with the management of configuration and monitoring performance. Topological mappings provide outlines of the components of the network and its connectivity. Application monitoring is not essential and proxy server troubleshooting is used for troubleshooting purposes.

QUESTION 331

Which of the following controls will MOST effectively detect the presence of bursts of errors in network transmissions?

- A. Parity check
- B. Echo check
- C. Block sum check
- D. Cyclic redundancy check

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The cyclic redundancy check (CRC) can check for a block of transmitted data. The workstations generate the CRC and transmit it with the data. The receiving workstation computes a CRC and compares it to the transmitted CRC. If both of them are equal, then the block is assumed error free, in this case (such as in parity error or echo check), multiple errors can be detected. In general, CRC can detect all single-bit and bubble-bit errors. Parity check (known as vertical redundancy check) also involves adding a bit (known as the parity bit) to each character during transmission. In this case, where there is a presence of bursts of errors (i.e., impulsing noise during high transmission rates), it has a reliability of approximately 50 percent. In higher transmission rates, this limitation is significant. Echo checks detect line errors by retransmitting data to the sending device for comparison with the original transmission.

QUESTION 332

Which of the following types of firewalls provide the GREATEST degree and granularity of control?

- A. Screening router
- B. Packet filter
- C. Application gateway
- D. Circuit gateway

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The application gateway is similar to a circuit gateway, but it has specific proxies for each service. To handle web services, it has an HTTP proxy that acts as an intermediary between externals and internals, but is specifically for HTTP. This means that it not only checks the packet IP addresses (layer 3) and the ports it is directed to (in this case port 80, or layer 4), it also checks every HTTP command (layers 5 and 7). Therefore, it works in a more detailed (granularity) way than the others. Screening router and packet filter (choices A and B) work at the protocol, service and/or port level. This means that they analyze packets from layers 3 and 4, and not from higher levels. A circuit gateway (choice D) is based on a proxy or program that acts as an intermediary between external and internal accesses. This means that during an external access, instead of opening a single connection to the internal server, two connections are established—one from the external server to the proxy (which conforms the circuit-gateway) and one from the proxy to the internal server. Layers 3 and 4 (IP and TCP) and some general features from higher protocols are used to perform these tasks.

QUESTION 333

Which of the following is MOST directly affected by network performance monitoring tools?

- A. Integrity
- B. Availability
- C. Completeness
- D. Confidentiality

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

In case of a disruption in service, one of the key functions of network performance monitoring tools is to ensure that the information has remained unaltered. It is a function of security monitoring to assure confidentiality by using such tools as encryption. However, the most important aspect of network performance is assuring the ongoing dependence on connectivity to run the business. Therefore, the characteristic that benefits the most from network monitoring is availability.

QUESTION 334

A review of wide area network (WAN) usage discovers that traffic on one communication line between sites, synchronously linking the master and standby database, peaks at 96 percent of the line capacity. An IS auditor should conclude that:

- A. analysis is required to determine if a pattern emerges that results in a service loss for a short period of time.
- B. WAN capacity is adequate for the maximum traffic demands since saturation has not been reached.
- C. the line should immediately be replaced by one with a larger capacity to provide approximately 85 percent saturation.
- D. users should be instructed to reduce their traffic demands or distribute them across all service hours to flatten bandwidth consumption.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The peak at 96 percent could be the result of a one-off incident, e.g., a user downloading a large amount of data; therefore, analysis to establish whether this is a regular pattern and what causes this behavior should be carried out before expenditure on a larger line capacity is recommended. Since the link provides for a standby

database, a short loss of this service should be acceptable. If the peak is established to be a regular occurrence without any other opportunities for mitigation (usage of bandwidth reservation protocol, or other types of prioritizing network traffic), the line should be replaced as there is the risk of loss of service as the traffic approaches 100 percent. If, however, the peak is a one-off or can be put in other time frames, then user education may be an option.

QUESTION 335

While reviewing the IT infrastructure, an IS auditor notices that storage resources are continuously being added. The IS auditor should:

- A. recommend the use of disk mirroring.
- B. review the adequacy of offsite storage.
- C. review the capacity management process.
- D. recommend the use of a compression algorithm.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Capacity management is the planning and monitoring of computer resources to ensure that available IT resources are used efficiently and effectively. Business criticality must be considered before recommending a disk mirroring solution and offsite storage is unrelated to the problem. Though data compression may save disk space, it could affect system performance.

QUESTION 336

In a small organization, an employee performs computer operations and, when the situation demands, program modifications. Which of the following should the IS auditor recommend?

- A. Automated logging of changes to development libraries
- B. Additional staff to provide separation of duties
- C. Procedures that verify that only approved program changes are implemented
- D. Access controls to prevent the operator from making program modifications

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

While it would be preferred that strict separation of duties be adhered to and that additional staff is recruited as suggested in choice B, this practice is not always possible in small organizations. An IS auditor must look at recommended alternative processes. Of the choices, C is the only practical one that has an impact. An IS auditor should recommend processes that detect changes to production source and object code, such as code comparisons, so the changes can be reviewed on a regular basis by a third party. This would be a compensating control process.

Choice A, involving logging of changes to development libraries, would not detect changes to production libraries. Choice D is in effect requiring a third party to do the changes, which may not be practical in a small organization.

QUESTION 337

Vendors have released patches fixing security flaws in their software. Which of the following should an IS auditor recommend in this situation?

- A. Assess the impact of patches prior to installation.
- B. Ask the vendors for a new software version with all fixes included.
- C. install the security patch immediately.
- D. Decline to deal with these vendors in the future.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The effect of installing the patch should be immediately evaluated and installation should occur based on the results of the evaluation. To install the patch without knowing what it might affect could easily cause problems. New software versions with fixes included are not always available and a full installation could be time consuming. Declining to deal with vendors does not take care of the flaw.

QUESTION 338

Which of the following controls would be MOST effective in ensuring that production source code and object code are synchronized?

- A. Release-to-release source and object comparison reports
- B. Library control software restricting changes to source code
- C. Restricted access to source code and object code
- D. Date and time-stamp reviews of source and object code

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Date and time-stamp reviews of source and object code would ensure that source code, which has been compiled, matches the production object code. This is the most effective way to ensure that the approved production source code is compiled and is the one being used.

QUESTION 339

Change management procedures are established by IS management to:

- A. control the movement of applications from the test environment to the production environment.
- B. control the interruption of business operations from lack of attention to unresolved problems.
- C. ensure the uninterrupted operation of the business in the event of a disaster.
- D. verify that system changes are properly documented.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Change management procedures are established by IS management to control the movement of applications from the test environment to the production environment. Problem escalation procedures control the interruption of business operations from lack of attention to unresolved problems, and quality assurance procedures verify that system changes are authorized and tested.

QUESTION 340

In regard to moving an application program from the test environment to the production environment, the BEST control would be to have the:

- A. application programmer copy the source program and compiled object module to the production libraries
- B. application programmer copy the source program to the production libraries and then have the production control group compile the program.
- C. production control group compile the object module to the production libraries using the source program in the test environment.
- D. production control group copy the source program to the production libraries and then compile the program.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The best control would be provided by having the production control group copy the source program to the production libraries and then compile the program.

QUESTION 341

An IS auditor reviewing database controls discovered that changes to the database during normal working hours were handled through a standard set of procedures. However, changes made after normal hours required only an abbreviated number of steps. In this situation, which of the following would be considered an adequate set of compensating controls?

- A. Allow changes to be made only with the DBA user account.
- B. Make changes to the database after granting access to a normal user account.
- C. Use the DBA user account to make changes, log the changes and review the change log the following day.
- D. Use the normal user account to make changes, log the changes and review the change log the following day.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The use of a database administrator (DBA) user account is normally set up to log all changes made and is most appropriate for changes made outside of normal hours. The use of a log, which records the changes, allows changes to be reviewed. The use of the DBA user account without logging would permit uncontrolled changes to be made to databases once access to the account was obtained. The use of a normal user account with no restrictions would allow uncontrolled changes to any of the databases. Logging would only provide information on changes made, but would not limit changes to only those that were authorized. Hence, logging coupled with review form an appropriate set of compensating controls.

QUESTION 342

Which of the following tests performed by an IS auditor would be the MOST effective in determining compliance with an organization's change control procedures?

- A. Review software migration records and verify approvals.
- B. Identify changes that have occurred and verify approvals.
- C. Review change control documentation and verify approvals.
- D. Ensure that only appropriate staff can migrate changes into production.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The most effective method is to determine through code comparisons what changes have been made and then verify that they have been approved. Change control records and software migration records may not have all changes listed. Ensuring that only appropriate staff can migrate changes into production is a key control process, but in itself does not verify compliance.

QUESTION 343

An IS auditor reviewing a database application discovers that the current configuration does not match the originally designed structure. Which of the following should be the IS auditor's next action?

- A. Analyze the need for the structural change.
- B. Recommend restoration to the originally designed structure.
- C. Recommend the implementation of a change control process.
- D. Determine if the modifications were properly approved.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor should first determine if the modifications were properly approved. Choices A, B and C are possible subsequent actions, should the IS auditor find that the structural modification had not been approved.

QUESTION 344

A programmer maliciously modified a production program to change data and then restored the original code. Which of the following would MOST effectively detect the malicious activity?

- A. Comparing source code
- B. Reviewing system log files
- C. Comparing object code
- D. Reviewing executable and source code integrity

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Reviewing system log files is the only trail that may provide information about the unauthorized activities in the production library. Source and object code comparisons are ineffective, because the original programs were restored and do not exist. Reviewing executable and source code integrity is an ineffective control, because integrity between the executable and source code is automatically maintained.

QUESTION 345

The purpose of code signing is to provide assurance that:

- A. the software has not been subsequently modified.
- B. the application can safely interface with another signed application.
- C. the signer of the application is trusted.
- D. the private key of the signer has not been compromised.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Code signing can only ensure that the executable code has not been modified after being signed. The other choices are incorrect and actually represent potential and exploitable weaknesses of code signing.

QUESTION 346

An IS auditor should recommend the use of library control software to provide reasonable assurance that:

- A. program changes have been authorized.
- B. only thoroughly tested programs are released.
- C. modified programs are automatically moved to production.
- D. source and executable code integrity is maintained.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Library control software should be used to separate test from production libraries in mainframe and/or client server environments. The main objective of library control software is to provide assurance that program changes have been authorized. Library control software is concerned with authorized program changes and would not automatically move modified programs into production and cannot determine whether programs have been thoroughly tested. Library control software provides reasonable assurance that the source code and executable code are matched at the time a source code is moved to production. However, subsequent events such as a hardware failure can result in a lack of consistency between source and executable code.

QUESTION 347

An organization has recently installed a security patch, which crashed the production server. To minimize the probability of this occurring again, an IS auditor should:

- A. apply the patch according to the patch's release notes.
- B. ensure that a good change management process is in place.
- C. thoroughly test the patch before sending it to production.
- D. approve the patch after doing a risk assessment.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IS auditor must review the change management process, including patch management procedures, and verify that the process has adequate controls and make suggestions accordingly. The other choices are part of a good change management process but are not an IS auditor's responsibility.

QUESTION 348

When reviewing procedures for emergency changes to programs, the IS auditor should verify that the procedures:

- A. allow changes, which will be completed using after-the-fact follow-up.
- B. allow undocumented changes directly to the production library.
- C. do not allow any emergency changes.
- D. allow programmers permanent access to production programs.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

There may be situations where emergency fixes are required to resolve system problems. This involves the use of special logon IDs that grant programmers temporary access to production programs during emergency situations. Emergency changes should be completed using after-the-fact follow-up procedures, which ensure that normal procedures are retroactively applied; otherwise, production may be impacted. Changes made in this fashion should be held in an emergency library from where they can be moved to the production library, following the normal change management process. Programmers should not directly alter the production library nor should they be allowed permanent access to production programs.

QUESTION 349

To determine if unauthorized changes have been made to production code the BEST audit procedure is to:

- A. examine the change control system records and trace them forward to object code files.
- B. review access control permissions operating within the production program libraries.
- C. examine object code to find instances of changes and trace them back to change control records.
- D. review change approved designations established within the change control system.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The procedure of examining object code files to establish instances of code changes and tracing these back to change control system records is a substantive test that directly addresses the risk of unauthorized code changes. The other choices are valid procedures to apply in a change control audit but they do not directly address the risk of unauthorized code changes.

QUESTION 350

The application systems of an organization using open-source software have no single recognized developer producing patches. Which of the following would be the MOST secure way of updating open-source software?

- A. Rewrite the patches and apply them
- B. Code review and application of available patches
- C. Develop in-house patches
- D. identify and test suitable patches before applying them

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Suitable patches from the existing developers should be selected and tested before applying them. Rewriting the patches and applying them is not a correct answer because it would require skilled resources and time to rewrite the patches. Code review could be possible but tests need to be performed before applying the patches. Since the system was developed outside the organization, the IT department may not have the necessary skills and resources to develop patches.

QUESTION 351

Which of the following processes should an IS auditor recommend to assist in the recording of baselines for software releases?

- A. Change management
- B. Backup and recovery
- C. incident management
- D. Configuration management

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The configuration management process may include automated tools that will provide an automated recording of software release baselines. Should the new release fail, the baseline will provide a point to which to return. The other choices do not provide the processes necessary for establishing software release baselines and are not related to software release baselines.

QUESTION 352

An IS auditor notes that patches for the operating system used by an organization are deployed by the IT department as advised by the vendor. The MOST significant concern an IS auditor should have with this practice is the nonconsideration by IT of:

- A. the training needs for users after applying the patch.
- B. any beneficial impact of the patch on the operational systems.
- C. delaying deployment until testing the impact of the patch.
- D. the necessity of advising end users of new patches.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Deploying patches without testing exposes an organization to the risk of system disruption or failure. Normally, there is no need for training or advising users when a new operating system patch has been installed. Any beneficial impact is less important than the risk of unavailability that could be avoided with proper testing.

QUESTION 353

In a small organization, developers may release emergency changes directly to production. Which of the following will BEST control the risk in this situation?

- A. Approve and document the change the next business day
- B. Limit developer access to production to a specific timeframe
- C. Obtain secondary approval before releasing to production
- D. Disable the compiler option in the production machine

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

It may be appropriate to allow programmers to make emergency changes as long as they are documented and approved after the fact. Restricting release time frame may help somewhat; however, it would not apply to emergency changes and cannot prevent unauthorized release of the programs. Choices C and D are not

relevant in an emergency situation.

QUESTION 354

Time constraints and expanded needs have been found by an IS auditor to be the root causes for recent violations of corporate data definition standards in a new business intelligence project. Which of the following is the MOST appropriate suggestion for an auditor to make?

- A. Achieve standards alignment through an increase of resources devoted to the project
- B. Align the data definition standards after completion of the project
- C. Delay the project until compliance with standards can be achieved
- D. Enforce standard compliance by adopting punitive measures against violators

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Provided that data architecture, technical, and operational requirements are sufficiently documented, the alignment to standards could be treated as a specific work package assigned to new project resources. The usage of nonstandard data definitions would lower the efficiency of the new development, and increase the risk of errors in critical business decisions. To change data definition standards after project conclusion (choice B) is risky and is not a viable solution. On the other hand, punishing the violators (choice D) or delaying the project (choice C) would be an inappropriate suggestion because of the likely damage to the entire project profitability.

QUESTION 355

After installing a network, an organization installed a vulnerability assessment tool or security scanner to identify possible weaknesses. Which is the MOST serious risk associated with such tools?

- A. Differential reporting
- B. False-positive reporting
- C. False-negative reporting
- D. Less-detail reporting

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

False-negative reporting on weaknesses means the control weaknesses in the network are not identified and therefore may not be addressed, leaving the network vulnerable to attack. False-positive reporting is one in which the controls are in place, but are evaluated as weak, which should prompt a rechecking of the controls. Less-detail reporting and differential reporting functions provided by these tools compare scan results over a period of time.

QUESTION 356

The FIRST step in managing the risk of a cyber-attack is to:

- A. assess the vulnerability impact.
- B. evaluate the likelihood of threats.
- C. identify critical information assets.
- D. estimate potential damage.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The first step in the managing risk is the identification and classification of critical information resources (assets). Once the assets have been identified, the process moves onto the identification of threats, vulnerabilities and calculation of potential damages.

QUESTION 357

Which of the following is the MOST effective method for dealing with the spreading of a network worm that exploits vulnerability in a protocol?

- A. Install the vendor's security fix for the vulnerability.
- B. Block the protocol traffic in the perimeter firewall.
- C. Block the protocol traffic between internal network segments.
- D. Stop the service until an appropriate security fix is installed.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Stopping the service and installing the security fix is the safest way to prevent the worm from spreading, if the service is not stopped, installing the fix is not the most effective method because the worm continues spreading until the fix becomes effective. Blocking the protocol on the perimeter does not stop the worm from spreading to the internal network(s). Blocking the protocol helps to slow down the spreading but also prohibits any software that utilizes it from working between segments.

QUESTION 358

The PRIMARY objective of performing a postincident review is that it presents an opportunity to:

- A. improve internal control procedures.
- B. harden the network to industry best practices.
- C. highlight the importance of incident response management to management.
- D. improve employee awareness of the incident response process.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A postincident review examines both the cause and response to an incident. The lessons learned from the review can be used to improve internal controls. Understanding the purpose and structure of postincident reviews and follow-up procedures enables the information security manager to continuously improve the security program. Improving the incident response plan based on the incident review is an internal (corrective) control. The network may already be hardened to industry best practices. Additionally, the network may not be the source of the incident. The primary objective is to improve internal control procedures, not to highlight the importance of incident response management (IRM), and an incident response (IR) review does not improve employee awareness.

QUESTION 359

The computer security incident response team (CSIRT) of an organization disseminates detailed descriptions of recent threats. An IS auditor's GREATEST concern should be that the users might:

- A. use this information to launch attacks.
- B. forward the security alert.
- C. implement individual solutions.
- D. fail to understand the threat.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: An organization's computer security incident response team (CSIRT) should disseminate recent threats, security guidelines and security updates to the users to assist them in understanding the security risk of errors and omissions. However, this introduces the risk that the users may use this information to launch attacks, directly or indirectly. An IS auditor should ensure that the CSIRT is actively involved with users to assist them in mitigation of risks arising from

security failures and to prevent additional security incidents resulting from the same threat. Forwarding the security alert is not harmful to the organization, implementing individual solutions is unlikely and users failing to understand the threat would not be a serious concern.

QUESTION 360

The MAIN criterion for determining the severity level of a service disruption incident is:

- A. cost of recovery.
- B. negative public opinion.
- C. geographic location.
- D. downtime.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The longer the period of time a client cannot be serviced, the greater the severity of the incident. The cost of recovery could be minimal yet the service downtime could have a major impact. Negative public opinion is a symptom of an incident. Geographic location does not determine the severity of the incident.

QUESTION 361

Which of the following would be an indicator of the effectiveness of a computer security incident response team?

- A. Financial impact per security incident
- B. Number of security vulnerabilities that were patched
- C. Percentage of business applications that are being protected
- D. Number of successful penetration tests

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The most important indicator is the financial impact per security incident. Choices B, C and D could be measures of effectiveness of security, but would not be a measure of the effectiveness of a response team.

QUESTION 362

An IS auditor evaluating the resilience of a high-availability network should be MOST concerned if:

- A. the setup is geographically dispersed.
- B. the network servers are clustered in a site.
- C. a hot site is ready for activation.
- D. diverse routing is implemented for the network.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A clustered setup in one location makes the entire network vulnerable to natural disasters or other disruptive events. Dispersed geographical locations and diverse routing provide backup if a site has been destroyed. A hot site would also be a good alternative for a single point-of-failure site.

QUESTION 363

Which of the following network components is PRIMARILY set up to serve as a security measure by preventing unauthorized traffic between different segments of the network?

- A. Firewalls
- B. Routers
- C. Layer 2 switches
- D. VLANs

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Firewall systems are the primary tool that enable an organization to prevent unauthorized access between networks. An organization may choose to deploy one or more systems that function as firewalls. Routers can filter packets based on parameters, such as source address, but are not primarily a security tool. Based on Media Access Control (MAC) addresses, layer 2 switches separate traffic in a port as different segments and without determining if it is authorized or unauthorized traffic. A virtual LAN (VLAN) is a functionality of some switches that allows them to switch the traffic between different ports as if they are in the same LAN. Nevertheless, they do not deal with authorized vs. unauthorized traffic.

QUESTION 364

A company is implementing a dynamic host configuration protocol (DHCP). Given that the following conditions exist, which represents the GREATEST concern?

- A. Most employees use laptops.
- B. A packet filtering firewall is used.
- C. The IP address space is smaller than the number of PCs.
- D. Access to a network port is not restricted.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Given physical access to a port, anyone can connect to the internal network. The other choices do not present

the exposure that access to a port does. DHCP provides convenience (an advantage) to the laptop users. Sharing IP addresses and the existence of a firewall can be security measures.

QUESTION 365

An IS auditor is performing a network security review of a telecom company that provides Internet connection services to shopping malls for their wireless customers. The company uses Wireless Transport Layer Security (WTLS) and Secure Sockets Layer (SSL) technology for protecting their customer's payment information. The IS auditor should be MOST concerned if a hacker:

- A. compromises the Wireless Application Protocol (WAP) gateway.
- B. installs a sniffing program in front of the server.
- C. steals a customer's PDA.
- D. listens to the wireless transmission.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

In a WAP gateway, the encrypted messages from customers must be decrypted to transmit over the Internet and vice versa. Therefore, if the gateway is compromised, all of the messages would be exposed. SSL protects the messages from sniffing on the Internet, limiting disclosure of the customer's information. WTLS provides authentication, privacy and integrity and prevents messages from eavesdropping.

QUESTION 366

Which of the following BEST reduces the ability of one device to capture the packets that are meant for another device?

- A. Filters
- B. Switches
- C. Routers
- D. Firewalls

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Switches are at the lowest level of network security and transmit a packet to the device to which it is addressed. This reduces the ability of one device to capture the packets that are meant for another device. Filters allow for some basic isolation of network traffic based on the destination addresses. Routers allow packets to be given or denied access based on the addresses of the sender and receiver and the type of packet. Firewalls are a collection of computer and network equipment used to allow communications to flow out of the organization and restrict communications flowing into the organization.

QUESTION 367

In a client-server system, which of the following control techniques is used to inspect activity from known or unknown users?

- A. Diskless workstations
- B. Data encryption techniques
- C. Network monitoring devices
- D. Authentication systems

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Network monitoring devices may be used to inspect activities from known or unknown users and can identify client addresses, which may assist in finding evidence of unauthorized access. This serves as a detective control. Diskless workstations prevent access control software from being bypassed. Data encryption techniques can help protect sensitive or propriety data from unauthorized access, thereby serving as a preventive control. Authentication systems may provide environment wide, logical facilities that can differentiate among users, before providing access to systems.

QUESTION 368

When reviewing system parameters, an IS auditor's PRIMARY concern should be that:

- A. they are set to meet security and performance requirements.
- B. changes are recorded in an audit trail and periodically reviewed.
- C. changes are authorized and supported by appropriate documents.
- D. access to parameters in the system is restricted.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary concern is to find the balance between security and performance. Recording changes in an audit trail and periodically reviewing them is a detective control; however, if parameters are not set according to business rules, monitoring of changes may not be an effective control. Reviewing changes to ensure they are supported by appropriate documents is also a detective control, if parameters are set incorrectly, the related documentation and the fact that these are authorized does not reduce the impact. Restriction of access to parameters ensures that only authorized staff can access the parameters; however, if the parameters are set incorrectly, restricting access will still have an adverse impact.

QUESTION 369

Which of the following is a control over component communication failure/errors?

- A. Restricting operator access and maintaining audit trails
- B. Monitoring and reviewing system engineering activity
- C. Providing network redundancy
- D. Establishing physical barriers to the data transmitted over the network

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Redundancy by building some form of duplication into the network components, such as a link, router or switch to prevent loss, delays or data duplication is a control over component communication failure or error. Other related controls are loop/echochecks to detect line errors, parity checks, error correction codes and

sequence checks. Choices A, B and D are communication network controls.

QUESTION 370

An installed Ethernet cable run in an unshielded twisted pair (UTP) network is more than 100 meters long. Which of the following could be caused by the length of the cable?

- A. Electromagnetic interference (EMI)
- B. Cross-talk
- C. Dispersion
- D. Attenuation

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Attenuation is the weakening of signals during transmission. When the signal becomes weak, it begins to read a 1 for a 0, and the user may experience communication problems. UTP faces attenuation around 100 meters. Electromagnetic interference (EMI) is caused by outside electromagnetic waves affecting the desired signals, which is not the case here. Cross-talk has nothing to do with the length of the UTP cable.

QUESTION 371

Which of the following line media would provide the BEST security for a telecommunication network?

- A. broadband network digital transmission
- B. Baseband network
- C. Dial-up
- D. Dedicated lines

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Dedicated lines are set apart for a particular user or organization. Since there is no sharing of lines or intermediate entry points, the risk of interception or disruption of telecommunications messages is lower.

QUESTION 372

Which of the following types of firewalls would BEST protect a network from an internet attack?

- A. Screened subnet firewall
- B. Application filtering gateway
- C. Packet filtering router
- D. Circuit-level gateway

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A screened subnet firewall would provide the best protection. The screening router can be a commercial router or a node with routing capabilities and the ability to allow or avoid traffic between nets or nodes based on addresses, ports, protocols, interfaces, etc. Application-level gateways are mediators between two entities that want to communicate, also known as proxy gateways. The application level (proxy) works at the application level, not just at a package level. The screening controls at the package level, addresses and ports, but does not see the contents of the package. A packet filtering router examines the header of every packet or data traveling between the internet and the corporate network.

QUESTION 373

Neural networks are effective in detecting fraud because they can:

- A. discover new trends since they are inherently linear.
- B. solve problems where large and general sets of training data are not obtainable.
- C. attack problems that require consideration of a large number of input variables.
- D. make assumptions about the shape of any curve relating variables to the output.

Correct Answer: C

Explanation

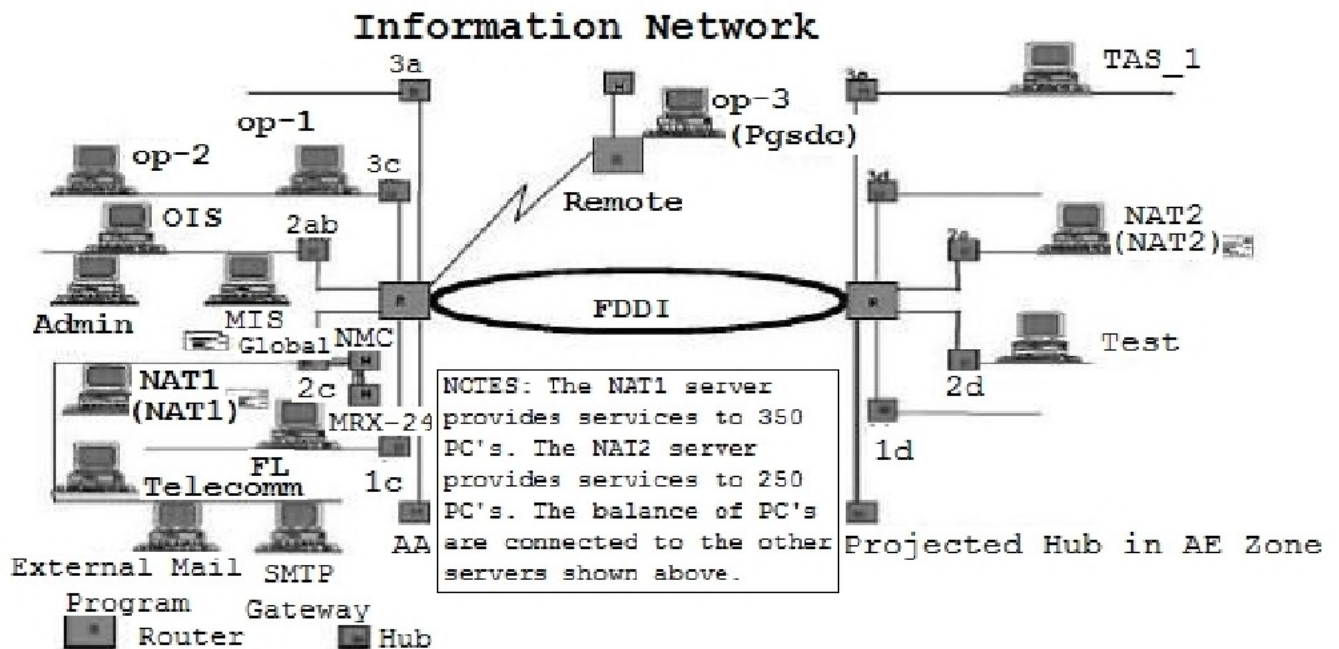
Explanation/Reference:

Section: Protection of Information Assets

Neural networks can be used to attack problems that require consideration of numerous input variables. They are capable of capturing relationships and patterns often missed by other statistical methods, but they will not discover new trends. Neural networks are inherently nonlinear and make no assumption about the shape of any curve relating variables to the output. Neural networks will not work well at solving problems for which sufficiently large and general sets of training data are not obtainable.

QUESTION 374

Assuming this diagram represents an internal facility and the organization is implementing a firewall protection program, where should firewalls be installed?



- A. No firewalls are needed
- B. Op-3 location only
- C. MIS (Global) and NAT2
- D. SMTP Gateway and op-3

Correct Answer: D

Explanation

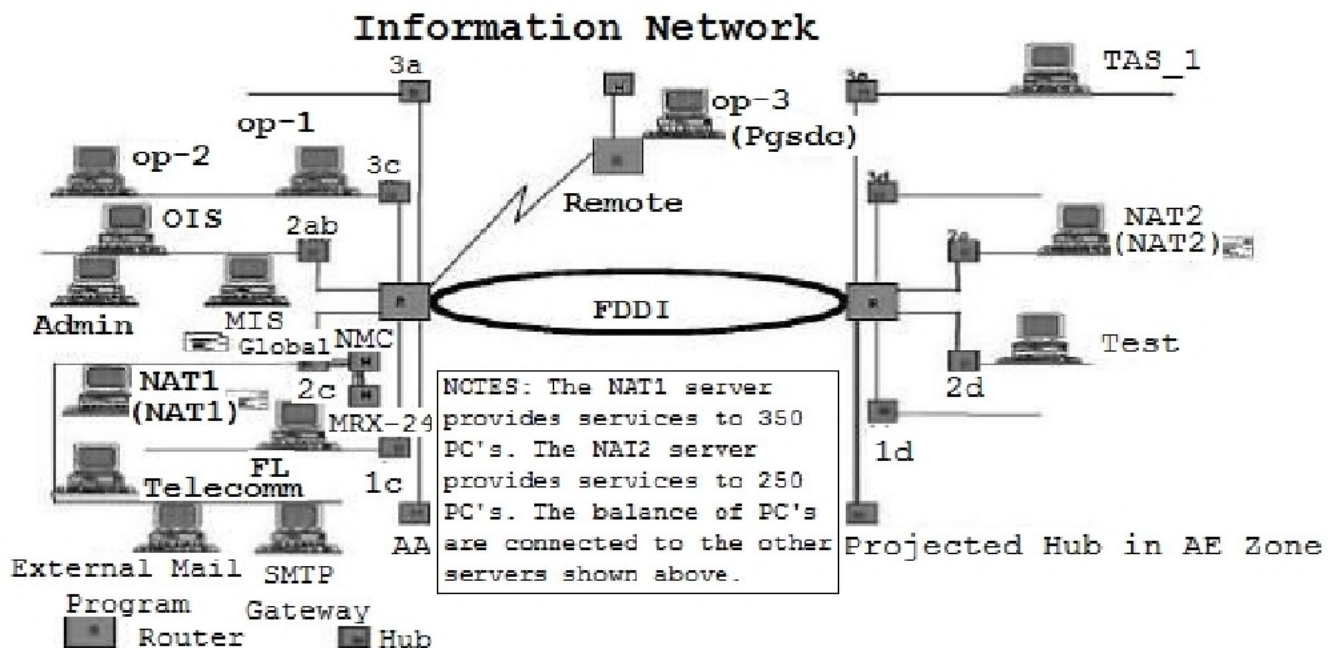
Explanation/Reference:

Section: Protection of Information Assets

The objective of a firewall is to protect a trusted network from an untrusted network; therefore, locations needing firewall implementations would be at the existence of the external connections. All other answers are incomplete or represent internal connections.

QUESTION 375

For locations 3a, 1d and 3d, the diagram indicates hubs with lines that appear to be open and active. Assuming that is true, what control, if any, should be recommended to mitigate this weakness?



- A. Intelligent hub
- B. Physical security over the hubs
- C. Physical security and an intelligent hub
- D. No controls are necessary since this is not a weakness

Correct Answer: C
Explanation

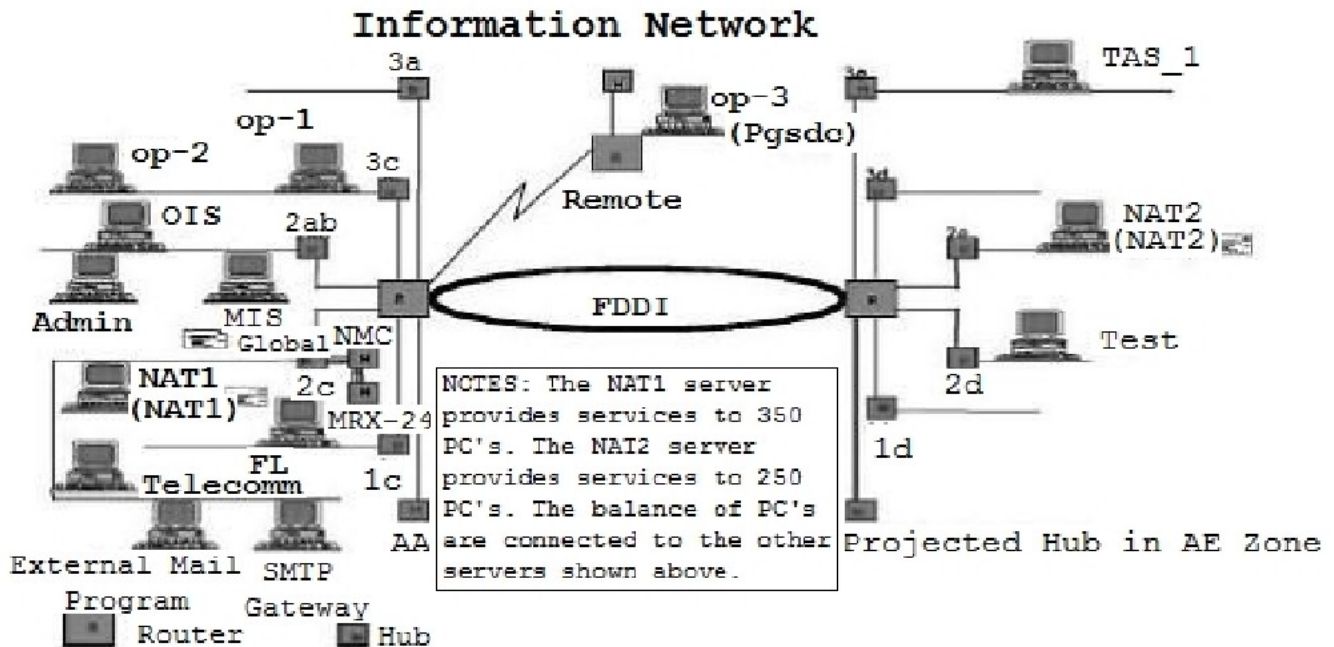
Explanation/Reference:

Section: Protection of Information Assets

Open hubs represent a significant control weakness because of the potential to access a network connection easily. An intelligent hub would allow the deactivation of a single port while leaving the remaining ports active. Additionally, physical security would also provide reasonable protection over hubs with active ports.

QUESTION 376

In the 2c area of the diagram, there are three hubs connected to each other. What potential risk might this indicate?



- A. Virus attack
- B. Performance degradation
- C. Poor management controls
- D. Vulnerability to external hackers

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Hubs are internal devices that usually have no direct external connectivity, and thus are not prone to hackers. There are no known viruses that are specific to hub attacks. While this situation may be an indicator of poor management controls, choice B is more likely when the practice of stacking hubs and creating more terminal

connections is used.

QUESTION 377

An organization provides information to its supply chain partners and customers through an extranet infrastructure. Which of the following should be the GREATEST concern to an IS auditor reviewing the firewall security architecture?

- A. A Secure Sockets Layer (SSL) has been implemented for user authentication and remote administration of the firewall.
- B. Firewall policies are updated on the basis of changing requirements.
- C. inbound traffic is blocked unless the traffic type and connections have been specifically permitted.
- D. The firewall is placed on top of the commercial operating system with all installation options.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The greatest concern when implementing firewalls on top of commercial operating systems is the potential presence of vulnerabilities that could undermine the security posture of the firewall platform itself. In most circumstances, when commercial firewalls are breached that breach is facilitated by vulnerabilities in the underlying operating system. Keeping all installation options available on the system further increases the risks of vulnerabilities and exploits. Using SSL for firewall administration (choice A) is important, because changes in user and supply chain partners' roles and profiles will be dynamic. Therefore, it is appropriate to maintain the firewall policies daily (choice B), and prudent to block all inbound traffic unless permitted (choice C).

QUESTION 378

In a client-server architecture, a domain name service (DNS) is MOST important because it provides the:

- A. address of the domain server.
- B. resolution service for the name/address.
- C. IP addresses for the internet.
- D. domain name system.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

DNS is utilized primarily on the Internet for resolution of the name/address of the web site. It is an Internet service that translates domain names into IP addresses. As names are alphabetic, they are easier to remember. However, the Internet is based on IP addresses. Every time a domain name is used, a DNS service must translate the name into the corresponding IP address. The DNS system has its own network, if one DNS server does not know how to translate a particular domain name, it asks another one, and so on, until the correct IP address is returned.

QUESTION 379

In what way is a common gateway interface (CGI) MOST often used on a webserver?

- A. Consistent way for transferring data to the application program and back to the user
- B. Computer graphics imaging method for movies and TV
- C. Graphic user interface for web design
- D. interface to access the private gateway domain

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The common gateway interface (CGI) is a standard way for a web server to pass a user's request to an application program and to move data back and forth to the user. When the user requests a web page (for example, by clicking on a highlighted word orienteering a web site address), the server sends back the requested page. However, when a user fills out a form on a web page and submits it, it usually needs to be processed by an application program. The web server typically passes the form information to a small application program that processes the data and may send back a confirmation message. This method, or convention, for passing data back and forth between the server and the application is called the common gateway interface (CGI). It is part of the web's HTTP protocol.

QUESTION 380

Receiving an EDI transaction and passing it through the communication's interface stage usually requires:

- A. translating and unbundling transactions.
- B. routing verification procedures.
- C. passing data to the appropriate application system.
- D. creating a point of receipt audit log.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The communication's interface stage requires routing verification procedures. Edi or ANSI X12 is a standard that must be interpreted by an application for transactions to be processed and then to be invoiced, paid and sent, whether they are for merchandise or services. There is no point sending and receiving EDI transactions if they cannot be processed by an internal system. Unpacking transactions and recording audit logs are important elements that help follow business rules and establish controls, but are not part of the communication's interface stage.

QUESTION 381

Which of the following would be considered an essential feature of a network management system?

- A. A graphical interface to map the network topology
- B. Capacity to interact with the Internet to solve the problems
- C. Connectivity to a help desk for advice on difficult issues
- D. An export facility for piping data to spreadsheets

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

To trace the topology of the network, a graphical interface would be essential. It is not necessary that each network be on the internet and connected to a help desk, while the ability to export to a spreadsheet is not an essential element.

QUESTION 382

The most likely error to occur when implementing a firewall is:

- A. incorrectly configuring the access lists.
- B. compromising the passwords due to social engineering.
- C. connecting a modem to the computers in the network.
- D. inadequately protecting the network and server from virus attacks.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An updated and flawless access list is a significant challenge and, therefore, has the greatest chance for errors at the time of the initial installation. Passwords do not apply to firewalls, a modem bypasses a firewall and a virus attack is not an element in implementing a firewall.

QUESTION 383

When reviewing the implementation of a LAN, an IS auditor should FIRST review the:

- A. node list.
- B. acceptance test report.
- C. network diagram.
- D. user's list.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

To properly review a LAN implementation, an IS auditor should first verify the network diagram and confirm the approval. Verification of nodes from the node list and the network diagram would be next, followed by a review of the acceptance test report and then the user's list.

QUESTION 384

Which of the following would be the MOST secure firewall system?

- A. Screened-host firewall
- B. Screened-subnet firewall
- C. Dual-homed firewall
- D. Stateful-inspection firewall

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A screened-subnet firewall, also used as a demilitarized zone (DMZ), utilizes two packet filtering routers and a bastion host. This provides the most secure firewall system, since it supports both network- and application- level security while defining a separate DMZ network. A screened-host firewall utilizes a packet filtering router and a bastion host. This approach implements basic network layer security (packet filtering) and application server security (proxy services). A dual- homed firewall system is a more restrictive form of a screened-host firewall system, configuring one interface for information servers and another for private network host computers. A stateful-inspection firewall working at the transport layer keeps track of the destination IP address of each packet that leaves the organization's internal network and allows a reply from the recorded IP

addresses.

QUESTION 385

Reconfiguring which of the following firewall types will prevent inward downloading of files through the File Transfer Protocol (FTP)?

- A. Circuit gateway
- B. Application gateway
- C. Packet filter
- D. Screening router

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An application gateway firewall is effective in preventing applications, such as FTPs, from entering the organization network. A circuit gateway firewall is able to prevent paths or circuits, not applications, from entering the organization's network. A packet filter firewall or screening router will allow or prevent access based on IP packets/address.

QUESTION 386

Which of the following applet intrusion issues poses the GREATEST risk of disruption to an organization?

- A. A program that deposits a virus on a client machine
- B. Applets recording keystrokes and, therefore, passwords
- C. Downloaded code that reads files on a client's hard drive
- D. Applets opening connections from the client machine

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An applet is a program downloaded from a web server to the client, usually through a web browser that provides functionality for database access, interactive web pages and communications with other users. Applets opening connections from the client machine to other machines on the network and damaging those machines, as a denial-of-service attack, pose the greatest threat to an organization and could disrupt business continuity. A program that deposits a virus on a client machine is referred to as a malicious attack (i.e., specifically meant to cause harm to a client machine), but may not necessarily result in a disruption of service. Applets that record keystrokes, and therefore, passwords, and downloaded code that reads files on a client's hard drive relate more to organizational privacy issues, and although significant, are less likely to cause a significant disruption of service.

QUESTION 387

Which of the following protocols would be involved in the implementation of a router and an interconnectivity device monitoring system?

- A. Simple Network Management Protocol
- B. File Transfer Protocol
- C. Simple Mail Transfer Protocol
- D. Telnet

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The Simple Network Management Protocol provides a means to monitor and control network devices and to manage configurations and performance. The File Transfer Protocol (FTP) transfers files from a computer on the Internet to the user's computer and does not have any functionality related to monitoring network devices. Simple Mail Transfer Protocol (SMTP) is a protocol for sending and receiving e-mail messages and does not provide any monitoring or management for network devices. Telnet is a standard terminal emulation protocol used for remote terminal connections, enabling users to log into remote systems and use resources as if they were connected to a local system; it does not provide any monitoring or management of network devices.

QUESTION 388

Java applets and ActiveX controls are distributed executable programs that execute in the background of a web browser client. This practice is considered reasonable when:

- A. a firewall exists.
- B. a secure web connection is used.
- C. the source of the executable file is certain.
- D. the host web site is part of the organization.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Acceptance of these mechanisms should be based on established trust. The control is provided by only knowing the source and then allowing the acceptance of the applets. Hostile applets can be received from anywhere. It is virtually impossible at this time to filter at this level. A secure web connection or firewall is considered an external defense. A firewall will find it more difficult to filter a specific file from a trusted source. A secure web connection provides confidentiality. Neither a secure web connection nor a firewall can identify an executable file as friendly. Hosting the web site as part of the organization is impractical. Enabling the acceptance of Java applets and/or Active X controls is an all-or- nothing proposition. The client will accept the program if the parameters are established to do so.

QUESTION 389

In large corporate networks having supply partners across the globe, network traffic may continue to rise. The infrastructure components in such environments should be scalable. Which of the following firewall architectures limits future scalability?

- A. Appliances
- B. Operating system-based
- C. Host-based
- D. Demilitarized

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The software for appliances is embedded into chips. Firmware-based firewall products cannot be moved to higher capacity servers. Firewall software that sits on an operating system can always be scalable due to its ability to enhance the power of servers. Host- based firewalls operate on top of the server operating system and are scalable. A demilitarized zone is a model of firewall implementation and is not a firewall architecture.

QUESTION 390

Which of the following types of transmission media provide the BEST security against unauthorized access?

- A. Copper wire
- B. Twisted pair
- C. Fiberoptic cables
- D. Coaxial cables

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Fiberoptic cables have proven to be more secure than the other media. Satellite transmission and copper wire can be violated with inexpensive equipment. Coaxial cable can also be violated more easily than other transmission media.

QUESTION 391

Which of the following is the BEST audit procedure to determine if a firewall is configured in compliance with an organization's security policy?

- A. Review the parameter settings.
- B. Interview the firewall administrator.
- C. Review the actual procedures.
- D. Review the device's log file for recent attacks.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A review of the parameter settings will provide a good basis for comparison of the actual configuration to the security policy and will provide audit evidence documentation. The other choices do not provide audit evidence as strong as choice A.

QUESTION 392

To determine how data are accessed across different platforms in a heterogeneous environment, an IS auditor should FIRST review:

- A. business software.
- B. infrastructure platform tools.
- C. application services.
- D. system development tools.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Projects should identify the complexities of the IT Infrastructure that can be simplified or isolated by the development of application services. Application services isolate system developers from the complexities of the IT infrastructure and offer common functionalities that are shared by many applications. Application

services take the form of interfaces, middleware, etc. Business software focuses on business processes, whereas application services bridge the gap between applications and the IT Infrastructure components. Infrastructure platform tools are related to core hardware and software components required for development of the IT infrastructure. Systems development tools represent development components of the IT infrastructure development.

QUESTION 393

During the requirements definition phase for a database application, performance is listed as a top priority. To access the DBMS files, which of the following

technologies should be recommended for optimal I/O performance?

- A. Storage area network (SAN)
- B. Network Attached Storage (NAS)
- C. Network file system (NFS v2)
- D. Common Internet File System (CIFS)

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

In contrast to the other options, in a SAN comprised of computers, FC switches or routers and storage devices, there is no computer system hosting and exporting its mounted file system for remote access, aside from special file systems. Access to information stored on the storage devices in a SAN is comparable to direct attached storage, which means that each block of data on a disk can be addressed directly, since the volumes of the storage device are handled as though they are local, thus providing optimal performance. The other options describe technologies in which a computer (or appliance) shares its information with other systems. To access the information, the complete file has to be read.

QUESTION 394

Reverse proxy technology for web servers should be deployed if:

- A. http servers' addresses must be hidden.
- B. accelerated access to all published pages is required.
- C. caching is needed for fault tolerance.
- D. bandwidth to the user is limited.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Reverse proxies are primarily designed to hide physical and logical internal structures from outside access. Complete URLs or URIs can be partially or completely redirected without disclosing which internal or DMZ server is providing the requested data. This technology might be used if a trade-off between security, performance and costs has to be achieved. Proxy servers cache some data but normally cannot cache all pages to be published because this depends on the kind of information the web servers provide. The ability to accelerate access depends on the speed of the back-end servers, i.e., those that are cached. Thus, without making further assumptions, a gain in speed cannot be assured, but visualization and hiding of internal structures can. If speed is an issue, a scale-out approach (avoiding adding additional delays by passing firewalls, involving more servers, etc.) would be a better solution. Due to the limited caching option, reverse proxies are not suitable for enhancing fault tolerance. User requests that are handled by reverse proxy servers are using exactly the same bandwidth as direct requests to the hosts providing the data.

QUESTION 395

When auditing a proxy-based firewall, an IS auditor should:

- A. verify that the firewall is not dropping any forwarded packets.
- B. review Address Resolution Protocol (ARP) tables for appropriate mapping between media access control (MAC) and IP addresses.
- C. verify that the filters applied to services such as HTTP are effective.
- D. test whether routing information is forwarded by the firewall.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A proxy-based firewall works as an intermediary (proxy) between the service or application and the client, it makes a connection with the client and opens a different connection with the server and, based on specific filters and rules, analyzes all the traffic between the two connections. Unlike a packet-filtering gateway, a proxy-based firewall does not forward any packets. Mapping between media access control (MAC) and IP addresses is a task for protocols such as Address Resolution Protocol/ Reverse Address Resolution Protocol (ARP/RARP).

QUESTION 396

An IS auditor should review the configuration of which of the following protocols to detect unauthorized mappings between the IP address and the media access control (MAC) address?

- A. Simple Object Access Protocol (SOAP)
- B. Address Resolution Protocol (ARP)
- C. Routing Information Protocol (RIP)
- D. Transmission Control Protocol (TCP)

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Address Resolution Protocol (ARP) provides dynamic address mapping between an IP address and hardware address. Simple Object Access Protocol (SOAP) is a platform-independent XML-based protocol, enabling applications to communicate with each other over the Internet, and does not deal with media access control (MAC) addresses. Routing Information Protocol (RIP) specifies how routers exchange routing table information. Transmission Control Protocol (TCP) enables two hosts to establish a connection and exchange streams of data.

QUESTION 397

An IS auditor examining the configuration of an operating system to verify the controls should review the:

- A. transaction logs.
- B. authorization tables.
- C. parameter settings.
- D. routing tables.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Parameters allow a standard piece of software to be customized for diverse environments and are important in determining how a system runs. The parameter settings should be appropriate to an organization's workload and control environment, improper implementation and/or monitoring of operating systems can result in undetected errors and corruption of the data being processed, as well as lead to unauthorized access and inaccurate logging of system usage. Transaction logs are used to analyze transactions in master and/or transaction files. Authorization tables are used to verify implementation of logical access controls and will not be of much help when reviewing control features of an operating system. Routing tables do not contain information about the operating system and, therefore, provide no information to aid in the evaluation of controls.

QUESTION 398

When reviewing an implementation of a VoIP system over a corporate WAN, an IS auditor should expect to find:

- A. an integrated services digital network (ISDN) data link.
- B. traffic engineering.
- C. wired equivalent privacy (WEP) encryption of data.
- D. analog phone terminals.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

To ensure that quality of service requirements are achieved, the Voice-over IP (VoIP) service over the wide area network (WAN) should be protected from packet losses, latency or jitter. To reach this objective, the network performance can be managed using statistical techniques such as traffic engineering. The standard bandwidth of an integrated services digital network (ISDN) data link would not provide the quality of services required for corporate VoIP services. WEP is an encryption scheme related to wireless networking. The VoIP phones are usually connected to a corporate local area network (LAN) and are not analog.

QUESTION 399

Which of the following is a feature of Wi-Fi Protected Access (WPA) in wireless networks?

- A. Session keys are dynamic
- B. Private symmetric keys are used
- C. Keys are static and shared
- D. Source addresses are not encrypted or authenticated

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

WPA uses dynamic session keys, achieving stronger encryption than wireless encryption privacy (WEP), which operates with static keys (same key is used for everyone in the wireless network). All other choices are weaknesses of WEP.

QUESTION 400

During the audit of a database server, which of the following would be considered the GREATEST exposure?

- A. The password does not expire on the administrator account
- B. Default global security settings for the database remain unchanged
- C. Old data have not been purged
- D. Database activity is not fully logged

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Default security settings for the database could allow issues like blank user passwords or passwords that were the same as the username. Logging all database activity is not practical. Failure to purge old data may present a performance issue but is not an immediate security concern. Choice A is an exposure but not as serious as B.

QUESTION 401

Which significant risk is introduced by running the file transfer protocol (FTP) service on a server in a demilitarized zone (DMZ)?

- A. A user from within could send a file to an unauthorized person.
- B. FTP services could allow a user to download files from unauthorized sources.
- C. A hacker may be able to use the FTP service to bypass the firewall.
- D. FTP could significantly reduce the performance of a DMZ server.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Since file transfer protocol (FTP) is considered an insecure protocol, it should not be installed on a server in a demilitarized zone (DMZ). FTP could allow an unauthorized user to gain access to the network. Sending files to an unauthorized person and the risk of downloading unauthorized files are not as significant as having a firewall breach. The presence of the utility does not reduce the performance of a DMZ server; therefore, performance degradation is not a threat.

QUESTION 402

The MAIN reason for requiring that all computer clocks across an organization be synchronized is to:

- A. prevent omission or duplication of transactions.
- B. ensure smooth data transition from client machines to servers.
- C. ensure that e-mail messages have accurate time stamps.
- D. support the incident investigation process.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

During an investigation of incidents, audit logs are used as evidence, and the time stamp information in them is useful. If the clocks are not synchronized, investigations will be more difficult because a time line of events might not be easily established. Time-stamping a transaction has nothing to do with the update itself. Therefore, the possibility of omission or duplication of transactions does not exist. Data transfer has nothing to do with the time stamp. While the time stamp on an e-mail may not be accurate, this is not a significant issue.

QUESTION 403

When reviewing the configuration of network devices, an IS auditor should FIRST identify:

- A. the best practices for the type of network devices deployed.
- B. whether components of the network are missing.
- C. the importance of the network device in the topology.
- D. whether subcomponents of the network are being used appropriately.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The first step is to understand the importance and role of the network device within the organization's network topology. After understanding the devices in the network, the best practice for using the device should be reviewed to ensure that there are no anomalies within the configuration. Identification of which component or subcomponent is missing or being used inappropriately can only be known upon reviewing and understanding the topology and the best practice for deployment of the device in the network.

QUESTION 404

Which of the following would be of MOST concern when determining if information assets are adequately safeguard during transport and disposal?

- A. Lack of password protection
- B. Lack of recent awareness training
- C. Lack of appropriate data classification
- D. Lack of appropriate labeling

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 405

Which of the following should an IS auditor expect to find when reviewing IT security policy?

- A. Assigned responsibility for safeguarding company assets
- B. A risk-based classification of systems
- C. An inventory of information assets
- D. Virus protection implementation strategies

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 406

Which of the following roles is BEST suited to assign classification to an information asset?

- A. The data owner
- B. The information security manager
- C. The data custodian
- D. The senior manager

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 407

Which of the following is the MOST important reason to classify a disaster recovery plan (DRP) as confidential?

- A. Reduce the risk of data leakage that could lead to an attack.
- B. Comply with business continuity best practice.
- C. Ensure compliance with the data classification policy.
- D. Protect the plan from unauthorized alteration.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 408

Which of the following would protect the confidentiality of information sent in email messages?

- A. Encryption
- B. Digital certificates
- C. Digital signatures
- D. Secure Hash Algorithm 1 (SHA-1)

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 409

What is the PRIMARY objective of implementing data classification?

- A. Employ data leakage prevention tools.
- B. Establish appropriate data protection methods.
- C. Create awareness among users.
- D. Establish appropriate encryption methods.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 410

Which of the following is a PRIMARY purpose of a privacy notice?

- A. To obtain permission from users for the organization to use personal information as it sees fit
- B. To indemnify the organization against litigation by users for the appropriation of personal information
- C. To establish the organization's accountability for the use and protection of personal information
- D. To ensure that the organization's privacy controls comply with the privacy laws of the user's region

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 411

Which of the following features of a library control software package would protect against unauthorized updating of source code?

- A. Access controls for source libraries
- B. Required approvals at each life cycle step
- C. Date and time stamping of source and object code
- D. Release-to-release comparison of source code

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 412

Which of the following roles is ULTIMATELY accountable for the protection of an organization's information?

- A. The board of directors
- B. The chief information security officer (CISO)
- C. The data owner
- D. The chief information officer (CIO)

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 413

A digital signature addresses which of the following concerns?

- A. Message copying
- B. Message theft
- C. Unauthorized reading
- D. Message alteration

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 414

Which combination of access controls provides the BEST physical protection for a server room?

- A. PIN and smart card
- B. User ID and PIN
- C. Card with a magnetic strip and a smart card
- D. Card with a magnetic strip and a shared PIN

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 415

Which of the following would BEST deter the theft of corporate information from a laptop?

- A. Install biometric access controls.
- B. Encrypt all data on the hard drive.
- C. Protect files with passwords.
- D. Encrypt the file allocation table (FAT).

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 416

Which of the following system deployments requires the cloud provider to assume the widest range of responsibilities for data protection?

- A. Database as a Service (DbaaS)
- B. Software as a Service (SaaS)
- C. Platform as a Service (PaaS)
- D. Infrastructure as a Service (IaaS)

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 417

Which of the following would MOST effectively minimize the risk of unauthorized online banking customer transactions due to phishing?

- A. A strong authentication mechanism
- B. Clear audit trails
- C. An intrusion prevention system (IPS)
- D. A customer awareness program

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 418

Which of the following would have the GREATEST impact on defining the classification levels for electronic documents?

- A. Value of information
- B. Volume of information
- C. Document archival requirements
- D. End user preferences

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 419

An IS auditor is reviewing an organization's implementation of a bring your own device (BYOD) program. Which of the following would be the BEST recommendation to help ensure sensitive data is protected if a device is in the possession of an unauthorized individual?

- A. Enable the location service feature on devices.
- B. Encrypt data on devices including storage media.
- C. Authenticate device users when accessing the corporate network.
- D. Enable remote wiping of critical data.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 420

When reviewing an organization's data protection practices, an IS auditor should be MOST concerned with a lack of:

- A. a security team.
- B. data classification.
- C. training manuals.
- D. data encryption.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 421

Which of the following is the BEST control to protect an organization's sensitive data when using a publicly available cloud storage service?

- A. Cryptographic hash function performed by the cloud vendor
- B. Transparent volume encryption offered by the cloud vendor
- C. Data encryption performed by the organization prior to uploading
- D. Transport layer security (TLS) between the cloud vendor and the organization

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 422

An IS audit concludes that entry to the computer room is appropriately controlled. The audit result provides assurance that:

- A. the theft of hardware is prevented.
- B. the confidentiality of data is protected.
- C. data leakage is prevented.
- D. unauthorized access is prevented.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 423

Which of the following BEST helps to ensure data integrity across system interfaces?

- A. Environment segregation
- B. System backups
- C. Reconciliations
- D. Access controls

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 424

When implementing a software product (middleware) to pass data between local area network (LAN) servers and the mainframe, the MOST critical control consideration is:

- A. cross-platform security authentication.
- B. time synchronization of databases.
- C. network traffic levels between platforms.
- D. time-stamping of transactions to facilitate recovery.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 425

Which of the following test approaches would utilize data analytics to test a dual approval payment control?

- A. Review payments completed in the past month that do not have a unique approver.
- B. Attempt to complete a payment without a secondary approval.
- C. Review users within the payment application who are assigned an approver role.
- D. Evaluate configuration settings for the secondary approval requirements.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 426

To mitigate the risk of exposing data through application programming interface (API) queries, which of the following design considerations is MOST important?

- A. Data minimalization
- B. Data quality
- C. Data retention
- D. Data integrity

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 427

Which of the following is the BEST way to transmit documents classified as confidential over the Internet?

- A. Hashing the document contents and destroying the hash value

- B. Sending documents as multiple packets over different network routes
- C. Converting documents to proprietary format before transmission
- D. Using a virtual private network (VPN)

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 428

An organization is designing an application programming interface (API) for business-to-business data sharing with a vendor. Which of the following is the BEST way to reduce the potential risk of data leakage?

- A. Implement a policy to require data transfer over hypertext transfer protocol (HTTP)
- B. Implement the API on a secure server and encrypt traffic between both organizations
- C. Restrict the allowable number of API calls within a specified period
- D. Conduct an independent review of the application architecture and service level agreements (SLAs)

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 429

Which of the following threats is MOST effectively controlled by a firewall?

- A. Network congestion
- B. Denial of service (DoS) attack
- C. Network sniffing
- D. Password cracking

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 430

Which of the following is the BEST way to mitigate the impact of ransomware attacks?

- A. Backing up data frequently
- B. Invoking the disaster recovery plan (DRP)
- C. Requiring password changes for administrative accounts
- D. Paying the ransom

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 431

During a post-incident review of a security breach, what type of analysis should an IS auditor expect to be performed by the organization's information security team?

- A. Gap analysis
- B. Business impact analysis (BIA)
- C. Qualitative risk analysis
- D. Root cause analysis

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 432

When reviewing a contract for a disaster recovery hot site, which of the following would be the MOST significant omission?

- A. Audit rights
- B. Testing procedures
- C. Exposure coverage
- D. Equipment provided

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 433

Which of the following is the BEST reason to utilize blockchain technology to record accounting transactions?

- A. Integrity of records
- B. Confidentiality of records

- C. Availability of records
- D. Distribution of records

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 434

Which of the following is the GREATEST risk associated with instant messaging?

- A. Data governance may become ineffective.
- B. Data classification procedures may not be followed.
- C. Data logging is more difficult.
- D. Data exfiltration is more likely to occur.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 435

When using a wireless device, which of the following BEST ensures confidential access to email via web mail?

- A. Simple object access protocol (SOAP)
- B. Hypertext transfer protocol secure (HTTPS)
- C. Extensible markup language (XML)
- D. Wired equivalent privacy (WEP)

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 436

Which of the following is an indication of possible hacker activity involving voice communications?

- A. A significant percentage of lines are busy during early morning and late afternoon hours.
- B. Outbound calls are found to significantly increase in frequency during non-business hours.
- C. Inbound calls experience significant fluctuations based on time-of-day and day-of-week.
- D. Direct inward system access (DISA) is found to be disabled on the company's exchange.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 437

Which of the following would provide the BEST evidence for use in a forensic investigation of an employee's hard drive?

- A. A file level copy of the hard drive
- B. Bit-stream copy of the hard drive
- C. Memory dump to an external hard drive
- D. Prior backups

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 438

Which of the following is the BEST way to minimize leakage of data in transit?

- A. Virtual local area network (VLAN)
- B. Storage encryption
- C. Virtual private network (VPN)
- D. Digital signature

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 439

The recovery time objective (RTO) is normally determined on the basis of the:

- A. criticality of the systems affected
- B. risk of occurrence
- C. acceptable downtime of the alternate site
- D. cost of recovery of all systems

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 440
Which of the following attacks is BEST detected by an intrusion detection system (IDS)?

- A. Spamming
- B. Spoofing
- C. Logic bomb
- D. System scanning

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 441
An organization has implemented application whitelisting in response to the discovery of a large amount of unapproved software. Which type of control has been deployed?

- A. Directive
- B. Preventive
- C. Detective
- D. Corrective

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 442
Which of the following controls MOST effectively reduces the risk associated with use of instant messaging (IM) in the workplace?

- A. Traffic encryption
- B. Session border controllers
- C. Network address translation
- D. Blocking peer-to-peer (P2P) clients

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 443
Which type of review is MOST important to conduct when an IS auditor is informed that a recent internal exploitation of a bug has been discovered in a business application?

- A. Forensic audit
- B. Penetration testing
- C. Server security audit
- D. Application security testing

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 444
Which of the following is the PRIMARY factor in determining a recovery time objective (RTO)?

- A. Cost of testing the business continuity plan (BCP)
- B. Downtime cost of disaster
- C. Cost of offsite backup premises
- D. Response time of the emergency action plan

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 445
Which of the following is an example of personally identifiable information (PII)?

- A. Office address
- B. Passport number
- C. Date of birth
- D. Marital status

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 446

Which of the following will MOST likely compromise the control provided by a digital signature created using RSA encryption?

- A. Deciphering the receiver's public key
- B. Obtaining the sender's private key
- C. Altering the plaintext message
- D. Reversing the hash function using the digest

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 447

Data anonymization helps to prevent which types of attacks in a big data environment?

- A. Man-in-the-middle
- B. Denial-of-service
- C. Correlation
- D. Spoofing

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 448

Which of the following is MOST important when creating a forensic image of a hard drive?

- A. Generating a content hash of the hard drive
- B. Requiring an independent third-party be present while imaging
- C. Securing a backup copy of the hard drive
- D. Choosing an industry-leading forensics software tool

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 449

Which of the following controls BEST mitigates the impact of a distributed denial of service (DDoS) attack against the controller in a software-defined network (SDN)?

- A. Implementing multiple physical SDN controllers
- B. Relocating virtualized network functions to physical infrastructure
- C. Hardening the operating system that hosts the SDN controller
- D. Implementing configuration management for SDN controllers

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 450

Which of the following would BEST enable an organization to provide indirect access to web applications?

- A. Web application proxy
- B. Web application programming interface (API)
- C. Web application server
- D. Web authentication services

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 451

An IS auditor finds an organization has a significant number of systems developed by end-users. Which of the following is the BEST recommendation to help mitigate the associated risks?

- A. Storing systems on a shared drive managed by IT
- B. Storing developed source code in a centralized repository
- C. Centralizing information technology procurement
- D. Using a formal development methodology

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 452

Which of the following is the MAIN advantage of using one-time passwords?

- A. They are suitable for e-commerce authentication.
- B. Passwords are hardware/software generated.
- C. An intercepted password would be of no use.
- D. The user does not need to remember passwords.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 453

An IS auditor suspects an organization's computer may have been used to commit a crime. Which of the following is the auditor's BEST course of action?

- A. Examine the computer to search for evidence supporting the suspicions.
- B. Notify local law enforcement of the potential crime before further investigation.
- C. Contact the incident response team to conduct an investigation.
- D. Advise management of the crime after the investigation.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 454

Which of the following would be considered a corrective control when designing the security of a data center?

- A. Perimeter fence
- B. Closed-circuit television (CCTV)
- C. Fire extinguisher
- D. Security guards

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 455

Which of the following is the MOST effective control to restrict the use of instant messaging (IM) within an organization?

- A. Intrusion detection system (IDS)
- B. Antivirus software
- C. Application-based firewall
- D. Packet filtering firewall

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 456

Which of the following is MOST likely to be spoofed in an email transmission?

- A. The identity of the sender
- B. The identity of the receiving host
- C. The path the message traveled through the Internet
- D. The identity of the sending host

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 457

Which of the following is the safest means of transmitting confidential information over the Internet?

- A. Send the data to a trusted third party to resend to the destination.
- B. Use asymmetric encryption and encrypt the data with a private key.
- C. Establish a virtual private network (VPN) between the source and the destination.
- D. Break the data into many packets and send it over different routes.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 458

Which of the following presents the GREATEST security risk to an organization using peer-to-peer (P2P) file-sharing networks?

- A. There is no audit trail for files residing outside of the organization.
- B. IP addresses are shared to create a connection.
- C. Penetration testing cannot identify issues with P2P file-sharing networks.
- D. Controls are difficult to apply to unstructured networks.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 459

Buffer overflow in an Internet environment is of particular concern to the IS auditor because it can:

- A. corrupt databases during the build.
- B. be used to obtain importer access to a system.
- C. cause the loss of critical data during processing.
- D. cause printers to lose some of the document text when printing.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 460

When connecting to an organization's intranet from the Internet, security against unauthorized access is BEST achieved by using:

- A. encryption.
- B. virtual private networks (VPNs).
- C. screening routers.
- D. proxy servers.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 461

Which of the following is an advantage of using electronic data interchange (EDI)?

- A. Contracts with the vendors are simplified.
- B. Transcription of information is reduced.
- C. Data validation is provided by the service provider.
- D. Multiple inputs of the same document are allowed at different locations.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 462

The risk that is created if a single sign-on is implemented for all systems is that a/an:

- A. user can bypass current access security.
- B. compromised password gives access to all systems.
- C. authorized user can bypass the security layers.
- D. user has equivalent access on all systems.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 463

Which of the following BEST addresses the availability of an online store?

- A. Online backups
- B. A mirrored site at another location
- C. RAID level 5 storage devices
- D. Clustered architecture

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 464

Which of the following BEST enables system resiliency for an e-commerce organization that requires a low recovery time objective (RTO) and a low recovery point objective (RPO)?

- A. Redundant arrays

- B. Nightly backups
- C. Remote backups
- D. Mirrored sites

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 465

Which of the following is the MOST important control to help minimize the risk of data leakage from calls made to a business-to-business application programming interface (API)?

- A. Providing API security awareness training to developers
- B. Deploying content inspection at the API gateway
- C. Implementing API server clusters
- D. Implementing an API versioning system

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 466

Which of the following functions should be performed by the application owners to ensure an adequate segregation of duties between IS and end users?

- A. System analysis
- B. Authorization of access to data
- C. Application programming
- D. Data administration

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets
The application owner is responsible for authorizing access to data. Application development and programming are functions of the IS department. Similarly, system analysis should be performed by qualified persons in IS who have knowledge of IS and user requirements. Data administration is a specialized function related to database management systems and should be performed by qualified database administrators.

QUESTION 467

Accountability for the maintenance of appropriate security measures over information assets resides with the:

- A. security administrator.
- B. systems administrator.
- C. data and systems owners.
- D. systems operations group.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets
Management should ensure that all information assets (data and systems) have an appointed owner who makes decisions about classification and access rights. System owners typically delegate day-to-day custodianship to the systems delivery/operations group and security responsibilities to a security administrator. Owners, however, remain accountable for the maintenance of appropriate security measures.

QUESTION 468

The GREATEST risk when end users have access to a database at its system level, instead of through the application, is that the users can:

- A. make unauthorized changes to the database directly, without an audit trail.
- B. make use of a system query language (SQL) to access information.
- C. remotely access the database.
- D. update data without authentication.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets
Having access to the database could provide access to database utilities, which can update the database without an audit trail and without using the application. Using SQL only provides read access to information, in a networked environment, accessing the database remotely does not make a difference. What is critical is what is possible or completed through this access. To access a database, it is necessary that a user is authenticated using a user ID.

QUESTION 469

To determine who has been given permission to use a particular system resource, an IS auditor should review:

- A. activity lists.
- B. access control lists.
- C. logon ID lists.
- D. password lists.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Access control lists are the authorization tables that document the users who have been given permission to use a particular system resource and the types of access they have been granted. The other choices would not document who has been given permission to use (access) specific system resources.

QUESTION 470

Which of the following is the MOST effective control when granting temporary access to vendors?

- A. Vendor access corresponds to the service level agreement (SLA).
- B. User accounts are created with expiration dates and are based on services provided.
- C. Administrator access is provided for a limited period.
- D. User IDs are deleted when the work is completed.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The most effective control is to ensure that the granting of temporary access is based on services to be provided and that there is an expiration date (hopefully automated) associated with each ID. The SLA may have a provision for providing access, but this is not a control; it would merely define the need for access. Vendors require access for a limited period during the time of service. However, it is important to ensure that the access during this period is monitored. Deleting these user, I Dafter the work is completed is necessary, but if not automated, the deletion could be overlooked.

QUESTION 471

During a logical access controls review, an IS auditor observes that user accounts are shared. The GREATEST risk resulting from this situation is that:

- A. an unauthorized user may use the ID to gain access.
- B. user access management is time consuming.
- C. passwords are easily guessed.
- D. user accountability may not be established.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The use of a single user ID by more than one individual precludes knowing who in fact used that ID to access a system; therefore, it is literally impossible to hold anyone accountable. All user IDs, not just shared IDs, can be used by unauthorized individuals. Access management would not be any different with shared IDs, and shared user IDs do not necessarily have easily guessed passwords.

QUESTION 472

Which of the following satisfies a two-factor user authentication?

- A. Iris scanning plus fingerprint scanning
- B. Terminal ID plus global positioning system (GPS)
- C. A smart card requiring the user's PIN
- D. User ID along with password

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A smart card addresses what the user has. This is generally used in conjunction with testing what the user knows, e.g., a keyboard password or personal identification number (PIN). Proving who the user is usually requires a biometrics method, such as fingerprint, iris scan or voice verification, to prove biology. This is not a two-factor user authentication, because it proves only who the user is. A global positioning system (GPS) receiver reports on where the user is. The use of an ID and password (what the user knows) is a single- factor user authentication.

QUESTION 473

What is the MOST effective method of preventing unauthorized use of data files?

- A. Automated file entry
- B. Tape librarian
- C. Access control software
- D. Locked library

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Access control software is an active control designed to prevent unauthorized access to data.

QUESTION 474

Which of the following is the PRIMARY safeguard for securing software and data within an information processing facility?

- A. Security awareness
- B. Reading the security policy
- C. Security committee
- D. Logical access controls

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

To retain a competitive advantage and meet basic business requirements, organizations must ensure that the integrity of the information stored on their computer systems preserve the confidentiality of sensitive data and ensure the continued availability of their information systems. To meet these goals, logical access controls

must be in place. Awareness (choice A) itself does not protect against unauthorized access or disclosure of information. Knowledge of an information systems security policy (choice B), which should be known by the organization's employees, would help to protect information, but would not prevent the unauthorized access of information. A security committee (choice C) is key to the protection of information assets, but would address security issues within a broader perspective.

QUESTION 475

When reviewing an organization's logical access security, which of the following should be of MOST concern to an IS auditor?

- A. Passwords are not shared.
- B. Password files are not encrypted.
- C. Redundant logon IDs are deleted.
- D. The allocation of logon IDs is controlled.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When evaluating the technical aspects of logical security, unencrypted files represent the greatest risk. The sharing of passwords, checking for the redundancy of logon IDs and proper logon ID procedures are essential, but they are less important than ensuring that the password files are encrypted.

QUESTION 476

Passwords should be:

- A. assigned by the security administrator for first time logon.
- B. changed every 30 days at the discretion of the user.
- C. reused often to ensure the user does not forget the password.
- D. displayed on the screen so that the user can ensure that it has been entered properly.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Initial password assignment should be done discretely by the security administrator. Passwords should be changed often (e.g., every 30 days); however, changing should not be voluntary, it should be required by the system. Systems should not permit previous passwords to be used again. Old passwords may have been compromised and would thus permit unauthorized access. Passwords should not be displayed in any form.

QUESTION 477

When performing an audit of access rights, an IS auditor should be suspicious of which of the following if allocated to a computer operator?

- A. Read access to data
- B. Delete access to transaction data files
- C. Logged read/execute access to programs
- D. Update access to job control language/script files

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Deletion of transaction data files should be a function of the application support team, not operations staff. Read access to production data is a normal requirement of a computer operator, as is logged access to programs and access to JCL to control job execution.

QUESTION 478

To prevent unauthorized entry to the data maintained in a dial-up, fast response system, an IS auditor should recommend:

- A. online terminals are placed in restricted areas.
- B. online terminals are equipped with key locks.
- C. ID cards are required to gain access to online terminals.
- D. online access is terminated after a specified number of unsuccessful attempts.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The most appropriate control to prevent unauthorized entry is to terminate connection after a specified number of attempts. This will deter access through the guessing of IDs and passwords. The other choices are physical controls, which are not effective in deterring unauthorized accesses via telephone lines.

QUESTION 479

An IS auditor conducting an access control review in a client-server environment discovers that all printing options are accessible by all users. In this situation, the IS auditor is MOST likely to conclude that:

- A. exposure is greater, since information is available to unauthorized users.
- B. operating efficiency is enhanced, since anyone can print any report at any time.
- C. operating procedures are more effective, since information is easily available.
- D. user friendliness and flexibility is facilitated, since there is a smooth flow of information among users.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Information in all its forms needs to be protected from unauthorized access. Unrestricted access to the report option results in an exposure. Efficiency and effectiveness are not relevant factors in this situation. Greater control over reports will not be accomplished since reports need not be in a printed form only. Information could be transmitted outside as electronic files, because print options allow for printing in an electronic form as well.

QUESTION 480

Sign-on procedures include the creation of a unique user ID and password. However, an IS auditor discovers that in many cases the username and password are the same. The BEST control to mitigate this risk is to:

- A. change the company's security policy.
- B. educate users about the risk of weak passwords.
- C. build in validations to prevent this during user creation and password change.
- D. require a periodic review of matching user ID and passwords for detection and correction.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The compromise of the password is the highest risk. The best control is a preventive control through validation at the time the password is created or changed. Changing the company's security policy and educating users about the risks of weak passwords only provides information to users, but does little to enforce this control. Requiring a periodic review of matching user ID and passwords for detection and ensuring correction is a detective control.

QUESTION 481

The PRIMARY objective of a logical access control review is to:

- A. review access controls provided through software.
- B. ensure access is granted per the organization's authorities.
- C. walk through and assess the access provided in the IT environment.
- D. provide assurance that computer hardware is adequately protected against abuse.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The scope of a logical access control review is primarily to determine whether or not access is granted per the organization's authorizations. Choices A and C relate to procedures of a logical access control review, rather than objectives. Choice D is relevant to a physical access control review.

QUESTION 482

Naming conventions for system resources are important for access control because they:

- A. ensure that resource names are not ambiguous.
- B. reduce the number of rules required to adequately protect resources.
- C. ensure that user access to resources is clearly and uniquely identified.
- D. ensure that internationally recognized names are used to protect resources.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: Naming conventions for system resources are important for the efficient administration of security controls. The conventions can be structured, so resources beginning with the same high-level qualifier can be governed by one or more generic rules. This reduces the number of rules required to adequately protect resources, which in turn facilitates security administration and maintenance efforts. Reducing the number of rules required to protect resources allows for the grouping of resources and files by application, which makes it easier to provide access. Ensuring that resource names are not ambiguous cannot be achieved through the use of naming conventions. Ensuring the clear and unique identification of user access to resources is handled by access control rules, not naming conventions. Internationally recognized names are not required to control access to resources. Naming conventions tend to be based on how each organization wants to identify its resources.

QUESTION 483

Which of the following exposures could be caused by a line grabbing technique?

- A. Unauthorized data access
- B. Excessive CPU cycle usage
- C. Lockout of terminal polling
- D. Multiplexor control dysfunction

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Line grabbing will enable eavesdropping, thus allowing unauthorized data access, it will not necessarily cause multiplexor dysfunction, excessive CPU usage or lockout of terminal polling.

QUESTION 484

Electromagnetic emissions from a terminal represent an exposure because they:

- A. affect noise pollution.
- B. disrupt processor functions.
- C. produce dangerous levels of electric current.
- D. can be detected and displayed.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Emissions can be detected by sophisticated equipment and displayed, thus giving unauthorized person access to data. They should not cause disruption of CPUs or effect noise pollution.

QUESTION 485

Security administration procedures require read-only access to:

- A. access control tables.
- B. security log files.
- C. logging options.
- D. user profiles.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Security administration procedures require read-only access to security log files to ensure that, once generated, the logs are not modified. Logs provide evidence and track suspicious transactions and activities. Security administration procedures require write access to access control tables to manage and update the privileges according to authorized business requirements. Logging options require write access to allow the administrator to update the way the transactions and user activities are monitored, captured, stored, processed and reported.

QUESTION 486

With the help of a security officer, granting access to data is the responsibility of:

- A. data owners.
- B. programmers.
- C. system analysts.
- D. librarians.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data owners are responsible for the use of data. Written authorization for users to gain access to computerized information should be provided by the data owners. Security administration with the owners' approval sets up access rules stipulating which users or group of users are authorized to access data or files and the level of authorized access (e.g., read or update).

QUESTION 487

The FIRST step in data classification is to:

- A. establish ownership.
- B. perform a criticality analysis.
- C. define access rules.
- D. create a data dictionary.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data classification is necessary to define access rules based on a need-to-do and need-to-know basis. The data owner is responsible for defining the access rules; therefore, establishing ownership is the first step in data classification. The other choices are incorrect. A criticality analysis is required for protection of data, which takes input from data classification. Access definition is complete after data classification and input for a data dictionary is prepared from the data classification process.

QUESTION 488

Which of the following provides the framework for designing and developing logical access controls?

- A. Information systems security policy
- B. Access control lists
- C. Password management
- D. System configuration files

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The information systems security policy developed and approved by an organization's top management is the basis upon which logical access control is designed and developed. Access control lists, password management and systems configuration files are tools for implementing the access controls.

QUESTION 489

A hacker could obtain passwords without the use of computer tools or programs through the technique of:

- A. social engineering.
- B. sniffers.
- C. back doors.
- D. Trojan horses.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Social engineering is based on the divulgence of private information through dialogues, interviews, inquiries, etc., in which a user may be indiscreet regarding their or someone else's personal data. A sniffer is a computer tool to monitor the traffic in networks. Back doors are computer programs left by hackers to exploit vulnerabilities. Trojan horses are computer programs that pretend to supplant a real program; thus, the functionality of the program is not authorized and is usually malicious in nature.

QUESTION 490

The reliability of an application system's audit trail may be questionable if:

- A. user IDs are recorded in the audit trail.

- B. the security administrator has read-only rights to the audit file.
- C. date and time stamps are recorded when an action occurs.
- D. users can amend audit trail records when correcting system errors.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An audit trail is not effective if the details in it can be amended.

QUESTION 491

Which of the following user profiles should be of MOST concern to an IS auditor when performing an audit of an EFT system?

- A. Three users with the ability to capture and verify their own messages
- B. Five users with the ability to capture and send their own messages
- C. Five users with the ability to verify other users and to send their own messages
- D. Three users with the ability to capture and verify the messages of other users and to send their own messages

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The ability of one individual to capture and verify messages represents an inadequate segregation, since messages can be taken as correct and as if they had already been verified.

QUESTION 492

An IS auditor performing an independent classification of systems should consider a situation where functions could be performed manually at a tolerable cost for an extended period of time as:

- A. critical
- B. vital.
- C. sensitive.
- D. noncritical.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Sensitive functions are best described as those that can be performed manually at a tolerable cost for an extended period of time. Critical functions are those that cannot be performed unless they are replaced by identical capabilities and cannot be replaced by manual methods. Vital functions refer to those that can be performed manually but only for a brief period of time; this is associated with lower costs of disruption than critical functions. Noncritical functions may be interrupted for an extended period of time at little or no cost to the company, and require little time or cost to restore.

QUESTION 493

The implementation of access controls FIRST requires:

- A. a classification of IS resources.
- B. the labeling of IS resources.
- C. the creation of an access control list.
- D. an inventory of IS resources.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 494

Which of the following is an example of the defense in-depth security principle?

- A. Using two firewalls of different vendors to consecutively check the incoming network traffic
- B. Using a firewall as well as logical access controls on the hosts to control incoming network traffic
- C. Having no physical signs on the outside of a computer center building
- D. Using two firewalls in parallel to check different types of incoming traffic

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Defense in-depth means using different security mechanisms that back each other up. When network traffic passes the firewall unintentionally, the logical access controls form a second line of defense. Using two firewalls of different vendors to consecutively check the incoming network traffic is an example of diversity in defense. The firewalls are the same security mechanisms. By using two different products the probability of both products having the same vulnerabilities is diminished. Having no physical signs on the outside of a computer center building is a single security measure. Using two firewalls in parallel to check different types of incoming traffic is a single security mechanism and therefore no different than having a single firewall checking all traffic.

QUESTION 495

Which of the following would be the BEST access control procedure?

- A. The data owner formally authorizes access and an administrator implements the user authorization tables.
- B. Authorized staff implements the user authorization tables and the data owner sanctions them.
- C. The data owner and an IS manager jointly create and update the user authorization tables.
- D. The data owner creates and updates the user authorization tables.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The data owner holds the privilege and responsibility for formally establishing the access rights. An IS administrator should then implement or update user authorization tables. Choice B alters the desirable order. Choice C is not a formal procedure for authorizing access.

QUESTION 496

Which of the following would MOST effectively reduce social engineering incidents?

- A. Security awareness training
- B. increased physical security measures
- C. E-mail monitoring policy
- D. intrusion detection systems

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Social engineering exploits human nature and weaknesses to obtain information and access privileges. By increasing employee awareness of security issues, it is possible to reduce the number of successful social engineering incidents. In most cases, social engineering incidents do not require the physical presence of the intruder. Therefore, increased physical security measures would not prevent the intrusion. An e-mail monitoring policy informs users that all e-mail in the organization is subject to monitoring; it does not protect the users from potential security incidents and intruders. Intrusion detection systems are used to detect irregular or abnormal traffic patterns.

QUESTION 497

An information security policy stating that 'the display of passwords must be masked or suppressed' addresses which of the following attack methods?

- A. Piggybacking
- B. Dumpster diving
- C. Shoulder surfing
- D. Impersonation

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

If a password is displayed on a monitor, any person nearby could look over the shoulder of the user to obtain the password. Piggybacking refers to unauthorized persons following, either physically or virtually, authorized persons into restricted areas. Masking the display of passwords would not prevent someone from tailgating an authorized person. This policy only refers to 'the display of passwords.' If the policy referred to 'the display and printing of passwords' then it would address shoulder surfing and dumpster diving (looking through an organization's trash for valuable information), impersonation refers to someone acting as an employee in an attempt to retrieve desired information.

QUESTION 498

To ensure compliance with a security policy requiring that passwords be a combination of letters and numbers, an IS auditor should recommend that:

- A. the company policy be changed.
- B. passwords are periodically changed.
- C. an automated password management tool be used.
- D. security awareness training is delivered.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The use of an automated password management tool is a preventive control measure. The software would prevent repetition (semantic) and would enforce syntactic rules, thus making the passwords robust. It would also provide a method for ensuring frequent changes and would prevent the same user from reusing their old password for a designated period of time. Choices A, B and D do not enforce compliance.

QUESTION 499

An IS auditor has identified the lack of an authorization process for users of an application. The IS auditor's main concern should be that:

- A. more than one individual can claim to be a specific user.
- B. there is no way to limit the functions assigned to users.
- C. user accounts can be shared.
- D. users have a need-to-know privilege.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Without an appropriate authorization process, it will be impossible to establish functional limits and accountability. The risk that more than one individual can claim to be a specific user is associated with the authentication processes, rather than with authorization. The risk that user accounts can be shared is associated with identification processes, rather than with authorization. The need-to-know basis is the best approach to assigning privileges during the authorization process.

QUESTION 500

An IS auditor reviewing digital rights management (DRM) applications should expect to find an extensive use for which of the following technologies?

- A. Digitalized signatures
- B. Hashing
- C. Parsing
- D. Steganography

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Steganography is a technique for concealing the existence of messages or information. An increasingly important stenographical technique is digital watermarking, which hides data within data, e.g., by encoding rights information in a picture or music file without altering the picture or music's perceivable aesthetic qualities. Digitalized signatures are not related to digital rights management. Hashing creates a message hash or digest, which is used to ensure the integrity of the message; it is usually considered a part of cryptography. Parsing is the process of splitting up a continuous stream of characters for analytical purposes, and is widely applied in the design of programming languages or in data entry editing.

QUESTION 501

The information security policy that states 'each individual must have their badge read at every controlled door' addresses which of the following attack methods?

- A. Piggybacking
- B. Shoulder surfing
- C. Dumpster diving
- D. Impersonation

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Piggybacking refers to unauthorized persons following authorized persons, either physically or virtually, into restricted areas. This policy addresses the polite behavior problem of holding doors open for a stranger, if every employee must have their badge read at every controlled door no unauthorized person could enter the sensitive area. Looking over the shoulder of a user to obtain sensitive information could be done by an unauthorized person who has gained access to areas using piggybacking, but this policy specifically refers to physical access control. Shoulder surfing would not be prevented by the implementation of this policy. Dumpster diving, looking through an organization's trash for valuable information, could be done outside the company's physical perimeter; therefore, this policy would not address this attack method. Impersonation refers to a social engineer acting as an employee, trying to retrieve the desired information. Some forms of social engineering attacks could join an impersonation attack and piggybacking, but this information security policy does not address the impersonation attack.

QUESTION 502

Which of the following presents an inherent risk with no distinct identifiable preventive controls?

- A. Piggybacking
- B. Viruses
- C. Data diddling
- D. Unauthorized application shutdown

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data diddling involves changing data before they are entered into the computer. It is one of the most common abuses, because it requires limited technical knowledge and occurs before computer security can protect the data. There are only compensating controls for data diddling. Piggybacking is the act of following an authorized person through a secured door and can be prevented by the use of deadman doors. Logical piggybacking is an attempt to gain access through someone who has the rights, e.g., electronically attaching to an authorized telecommunication link to possibly intercept transmissions. This could be prevented by encrypting the message. Viruses are malicious program code inserted into another executable code that can self-replicate and spread from computer to computer via sharing of computer diskettes, transfer of logic over telecommunication lines or direct contact with an infected machine. Antiviral software can be used to protect the computer against viruses. The shutdown of an application can be initiated through terminals or microcomputers connected directly (online) or indirectly (dial-up line) to the computer. Only individuals knowing the high-level logon ID and password can initiate the shutdown process, which is effective if there are proper access controls.

QUESTION 503

Which of the following is a general operating system access control function?

- A. Creating database profiles
- B. Verifying user authorization at a field level
- C. Creating individual accountability
- D. Logging database access activities for monitoring access violation

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Creating individual accountability is the function of the general operating system. Creating database profiles, verifying user authorization at a field level and logging database access activities for monitoring access violations are all database-level access control functions.

QUESTION 504

Which of the following BEST restricts users to those functions needed to perform their duties?

- A. Application level access control
- B. Data encryption
- C. Disabling floppy disk drives
- D. Network monitoring device

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The use of application-level access control programs is a management control that restricts access by limiting users to only those functions needed to perform their duties. Data encryption and disabling floppy disk drives can restrict users to specific functions, but are not the best choices. A network monitoring device is a detective control, not a preventive control.

QUESTION 505

For a discretionary access control to be effective, it must:

- A. operate within the context of mandatory access controls.
- B. operate independently of mandatory access controls.
- C. enable users to override mandatory access controls when necessary.
- D. be specifically permitted by the security policy.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Mandatory access controls are prohibitive; anything that is not expressly permitted is forbidden. Only within this context do discretionary controls operate, prohibiting still more access with the same exclusionary principle. When systems enforce mandatory access control policies, they must distinguish between these and the mandatory access policies that offer more flexibility.

Discretionary controls do not override access controls and they do not have to be permitted in the security policy to be effective.

QUESTION 506

An IS auditor examining a biometric user authentication system establishes the existence of a control weakness that would allow an unauthorized individual to update the centralized database on the server that is used to store biometric templates. Of the following, which is the BEST control against this risk?

- A. Kerberos
- B. Vitality detection
- C. Multimodal biometrics
- D. Before-image/after-image logging

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Kerberos is a network authentication protocol for client-server applications that can be used to restrict access to the database to authorized users. Choices B and C are incorrect because vitality detection and multimodal biometrics are controls against spoofing and mimicry attacks. Before-image/after-image logging of database transactions is a detective control, as opposed to Kerberos, which is a preventative control.

QUESTION 507

From a control perspective, the PRIMARY objective of classifying information assets is to:

- A. establish guidelines for the level of access controls that should be assigned.
- B. ensure access controls are assigned to all information assets.
- C. assist management and auditors in risk assessment.
- D. identify which assets need to be insured against losses.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Information has varying degrees of sensitivity and criticality in meeting business objectives. By assigning classes or levels of sensitivity and criticality to information resources, management can establish guidelines for the level of access controls that should be assigned. End user management and the security administrator will use these classifications in their risk assessment process to assign a given class to each asset.

QUESTION 508

An organization has been recently downsized, in light of this, an IS auditor decides to test logical access controls. The IS auditor's PRIMARY concern should be that:

- A. all system access is authorized and appropriate for an individual's role and responsibilities.
- B. management has authorized appropriate access for all newly-hired individuals.
- C. only the system administrator has authority to grant or modify access to individuals.
- D. access authorization forms are used to grant or modify access to individuals.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The downsizing of an organization implies a large number of personnel actions over a relatively short period of time. Employees can be assigned new duties while retaining some or all of their former duties. Numerous employees may be laid off. The auditor should be concerned that an appropriate segregation of duties is maintained, that access is limited to what is required for an employee's role and responsibilities, and that access is revoked for those that are no longer employed by the organization. Choices B, C and D are all potential concerns of an IS auditor, but in light of the particular risks associated with a downsizing, should not be the primary concern.

QUESTION 509

The logical exposure associated with the use of a checkpoint restart procedure is:

- A. denial of service.
- B. an asynchronous attack
- C. wire tapping.
- D. computer shutdown.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Asynchronous attacks are operating system-based attacks. A checkpoint restart is a feature that stops a program at specified intermediate points for later restart in an orderly manner without losing data at the checkpoint. The operating system saves a copy of the computer programs and data in their current state as well as several system parameters describing the mode and security level of the program at the time of stoppage. An asynchronous attack occurs when an individual with access to this information is able to gain access to the checkpoint restart copy of the system parameters and change those parameters such that upon restart the program would function at a higher-priority security level.

QUESTION 510

Inadequate programming and coding practices introduce the risk of:

- A. phishing.
- B. buffer overflow exploitation.
- C. SYN flood.
- D. brute force attacks.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Buffer overflow exploitation may occur when programs do not check the length of the data that are input into a program. An attacker can send data that exceed the length of a buffer and override part of the program with malicious code. The countermeasure is proper programming and good coding practices. Phishing, SYN flood and brute force attacks happen independently of programming and coding practices.

QUESTION 511

Which of the following would prevent unauthorized changes to information stored in a server's log?

- A. Write-protecting the directory containing the system log
- B. Writing a duplicate log to another server
- C. Daily printing of the system log
- D. Storing the system log in write-once media

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Storing the system log in write-once media ensures the log cannot be modified. Write-protecting the system log does not prevent deletion or modification, since the superuser or users that have special permission can override the write protection. Writing a duplicate log to another server or daily printing of the system log cannot prevent unauthorized changes.

QUESTION 512

After reviewing its business processes, a large organization is deploying a new web application based on a VoIP technology. Which of the following is the MOST appropriate approach for implementing access control that will facilitate security management of the VoIP web application?

- A. Fine-grained access control
- B. Role-based access control (RBAC)
- C. Access control lists
- D. Network/service access control

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Authorization in this VoIP case can best be addressed by role-based access control (RBAC) technology. RBAC is easy to manage and can enforce strong and efficient access controls in large-scale web environments including VoIP implementation. Access control lists and fine-grained access control on VoIP web applications do not scale to enterprise wide systems, because they are primarily based on individual user identities and their specific technical privileges. Network/service addresses VoIP availability but does not address application-level access or authorization.

QUESTION 513

In an online banking application, which of the following would BEST protect against identity theft?

- A. Encryption of personal password
- B. Restricting the user to a specific terminal
- C. Two-factor authentication
- D. Periodic review of access logs

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Two-factor authentication requires two independent methods for establishing identity and privileges. Factors include something you know, such as a password; something you have, such as a token; and something you are, which is biometric. Requiring two of these factors makes identity theft more difficult. A password could be guessed or broken. Restricting the user to a specific terminal is not a practical alternative for an online application. Periodic review of access logs is a detective control and does not protect against identity theft.

QUESTION 514

Which of the following is the BEST method for preventing the leakage of confidential information in a laptop computer?

- A. Encrypt the hard disk with the owner's public key.
- B. Enable the boot password (hardware-based password).
- C. Use a biometric authentication device.
- D. Use two-factor authentication to logon to the notebook.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Only encryption of the data with a secure key will prevent the loss of confidential information. In such a case, confidential information can be accessed only with knowledge of the owner's private key, which should never be shared. Choices B, C and D deal with authentication and not with confidentiality of information. An individual can remove the hard drive from the secured laptop and install it on an unsecured computer, gaining access to the data.

QUESTION 515

The responsibility for authorizing access to application data should be with the:

- A. data custodian.
- B. database administrator (DBA).
- C. data owner.
- D. security administrator.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data owners should have the authority and responsibility for granting access to the data and applications for which they are responsible. Data custodians are responsible only for storing and safeguarding the data. The database administrator (DBA) is responsible for managing the database and the security administrator is responsible for implementing and maintaining IS security. The ultimate responsibility for data resides with the data owner.

QUESTION 516

During an audit of the logical access control of an ERP financial system an IS auditor found some user accounts shared by multiple individuals. The user IDs were based on roles rather than individual identities. These accounts allow access to financial transactions on the ERP. What should the IS auditor do next?

- A. Look for compensating controls.
- B. Review financial transactions logs.
- C. Review the scope of the audit.
- D. Ask the administrator to disable these accounts.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The best logical access control practice is to create user IDs for each individual to define accountability. This is possible only by establishing a one-to-one relationship between IDs and individuals. However, if the user IDs are created based on role designations, an IS auditor should first understand the reasons and then evaluate the effectiveness and efficiency of compensating controls. Reviewing transactions logs is not relevant to an audit of logical access control nor is reviewing the scope of the audit relevant. Asking the administrator to disable the shared accounts should not be recommended by an IS auditor before understanding the reasons and evaluating the compensating controls. It is not an IS auditor's responsibility to ask for disabling accounts during an audit.

QUESTION 517

Minimum password length and password complexity verification are examples of:

- A. detection controls.
- B. control objectives.
- C. audit objectives.
- D. control procedures.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Control procedures are practices established by management to achieve specific control objectives. Password controls are preventive controls, not detective controls. Control objectives are declarations of expected results from implementing controls and audit objectives are the specific goals of an audit.

QUESTION 518

An IS auditor finds that a DBA has read and write access to production data. The IS auditor should:

- A. accept the DBA access as a common practice.
- B. assess the controls relevant to the DBA function.
- C. recommend the immediate revocation of the DBA access to production data.
- D. review user access authorizations approved by the DBA.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

It is good practice when finding a potential exposure to look for the best controls. Though granting the database administrator (DBA) access to production data might be a common practice, the IS auditor should evaluate the relevant controls. The DBA should have access based on a need-to-know and need-to-do basis; therefore, revocation may remove the access required. The DBA, typically, may need to have access to some production data. Granting user authorizations is the responsibility of the data owner and not the DBA.

QUESTION 519

When using a universal storage bus (USB) flash drive to transport confidential corporate data to an offsite location, an effective control would be to:

- A. carry the flash drive in a portable safe.
- B. assure management that you will not lose the flash drive.
- C. request that management deliver the flash drive by courier.
- D. encrypt the folder containing the data with a strong key.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Encryption, with a strong key, is the most secure method for protecting the information on the flash drive. Carrying the flash drive in a portable safe does not guarantee the safety of the information in the event that the safe is stolen or lost. No matter what measures you take, the chance of losing the flash drive still exists. It is possible that a courier might lose the flash drive or that it might be stolen.

QUESTION 520

A business application system accesses a corporate database using a single ID and password embedded in a program. Which of the following would provide

efficient access control over the organization's data?

- A. Introduce a secondary authentication method such as card swipe
- B. Apply role-based permissions within the application system
- C. Have users input the ID and password for each database transaction
- D. Set an expiration period for the database password embedded in the program

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When a single ID and password are embedded in a program, the best compensating control would be a sound access control over the application layer and procedures to ensure access to data is granted based on a user's role. The issue is user permissions, not authentication, therefore adding a stronger authentication does not improve the situation. Having a user input the ID and password for access would provide a better control because a database log would identify the initiator of the activity. However, this may not be efficient because each transaction would require a separate authentication process. It is a good practice to set an expiration date for a password. However, this might not be practical for an ID automatically logged in from the program. Often, this type of password is set not to expire.

QUESTION 521

Which of the following is the BEST practice to ensure that access authorizations are still valid?

- A. information owner provides authorization for users to gain access
- B. identity management is integrated with human resource processes
- C. information owners periodically review the access controls
- D. An authorization matrix is used to establish validity of access

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Personnel and departmental changes can result in authorization creep and can impact the effectiveness of access controls. Many times when personnel leave an organization, or employees are promoted, transferred or demoted, their system access is not fully removed, which increases the risk of unauthorized access. The best practices for ensuring access authorization is still valid is to integrate identity management with human resources processes. When an employee transfers to a different function, access rights are adjusted at the same time.

QUESTION 522

A technical lead who was working on a major project has left the organization. The project manager reports suspicious system activities on one of the servers that is accessible to the whole team. What would be of GREATEST concern if discovered during a forensic investigation?

- A. Audit logs are not enabled for the system
- B. A logon ID for the technical lead still exists
- C. Spyware is installed on the system
- D. A Trojan is installed on the system

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Audit logs are critical to the investigation of the event; however, if not enabled, misuse of the logon ID of the technical lead and the guest account could not be established. The logon ID of the technical lead should have been deleted as soon as the employee left the organization but, without audit logs, misuse of the ID is difficult to prove. Spyware installed on the system is a concern but could have been installed by any user and, again, without the presence of logs, discovering who installed the spyware is difficult. A Trojan installed on the system is a concern, but it can be done by any user as it is accessible to the whole group and, without the presence of logs, investigation would be difficult.

QUESTION 523

An organization is using an enterprise resource management (ERP) application. Which of the following would be an effective access control?

- A. User-level permissions
- B. Role-based
- C. Fine-grained
- D. Discretionary

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Role-based access controls the system access by defining roles for a group of users. Users are assigned to the various roles and the access is granted based on the user's role. User-level permissions for an ERP

system would create a larger administrative overhead. Fine-grained access control is very difficult to implement and maintain in the context of a large enterprise. Discretionary access control may be configured or modified by the users or data owners, and therefore may create inconsistencies in the access control management.

QUESTION 524

What should be the GREATEST concern to an IS auditor when employees use portable media (MP3 players, flash drives)?

- A. The copying of sensitive data on them
- B. The copying of songs and videos on them
- C. The cost of these devices multiplied by all the employees could be high
- D. They facilitate the spread of malicious code through the corporate network

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The MAIN concern with MP3 players and flash drives is data leakage, especially sensitive information. This could occur if the devices were lost or stolen. The risk when copying songs and videos is copyright infringement, but this is normally a less important risk than information leakage. Choice C is hardly an issue because employees normally buy the portable media with their own funds. Choice D is a possible risk, but not as important as information leakage and can be reduced by other controls.

QUESTION 525

An IS auditor should expect the responsibility for authorizing access rights to production data and systems to be entrusted to the:

- A. process owners.
- B. system administrators.
- C. security administrator.
- D. data owners.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Data owners are primarily responsible for safeguarding the data and authorizing access to production data on a need-to-know basis.

QUESTION 526

An IS auditor has completed a network audit. Which of the following is the MOST significant logical security finding?

- A. Network workstations are not disabled automatically after a period of inactivity.
- B. Wiring closets are left unlocked
- C. Network operating manuals and documentation are not properly secured.
- D. Network components are not equipped with an uninterruptible power supply.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Choice A is the only logical security finding. Network logical security controls should be in place to restrict, identify, and report authorized and unauthorized users of the network. Disabling inactive workstations restricts users of the network. Choice D is an environmental issue and choices B and C are physical security issues. Choices B, C and D should be reported to the appropriate entity.

QUESTION 527

Which of the following would MOST effectively enhance the security of a challenge- response based authentication system?

- A. Selecting a more robust algorithm to generate challenge strings
- B. implementing measures to prevent session hijacking attacks
- C. increasing the frequency of associated password changes
- D. increasing the length of authentication strings

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Challenge response-based authentication is prone to session hijacking or man-in-the- middle attacks. Security management should be aware of this and engage in risk assessment and control design when they employ this technology. Selecting a more robust algorithm will enhance the security; however, this may not be as important in terms of risk when compared to man-in- the-middle attacks. Choices C and D are good security practices; however, they are not as effective a preventive measure. Frequently changing passwords is a good security practice; however, the exposures lurking in communication pathways may pose a greater risk.

QUESTION 528

Which of the following should an IS auditor recommend for the protection of specific sensitive information stored in the data warehouse?

- A. implement column- and row-level permissions
- B. Enhance user authentication via strong passwords
- C. Organize the data warehouse into subject matter-specific databases
- D. Log user access to the data warehouse

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Choice A specifically addresses the question of sensitive data by controlling what information users can access. Column-level security prevents users from seeing one or more attributes on a table. With row-level security a certain grouping of information on a table is restricted; e.g., if a table held details of employee salaries, then a restriction could be put in place to ensure that, unless specifically authorized, users could not view the salaries of executive staff. Column- and row-level security can be achieved in a relational database by allowing users to access logical representations of data rather than physical tables. This 'fine-grained' security model is likely to offer the best balance between information protection while still supporting a wide range of analytical and reporting uses. Enhancing user authentication via strong passwords is a security control that should apply to all users of the data warehouse and does not specifically address protection of sensitive data. Organizing a data warehouse into subject-specific databases is a potentially useful practice but, in itself, does not adequately protect sensitive data. Database-level security is normally too 'coarse' a level to efficiently and effectively protect information. For example, one database may hold information that needs to be restricted

such as employee salary and customer profitability details while other information such as employee department may need to be legitimately accessed by a large number of users. Organizing the data warehouse into subject matter-specific databases is similar to user access in that this control should generally apply. Extra attention could be devoted to reviewing access to tables with sensitive data, but this control is not sufficient without strong preventive controls at the column and row level. For choice D, logging user access is important, but it is only a detective control that will not provide adequate protection to sensitive information.

QUESTION 529

The responsibility for authorizing access to a business application system belongs to the:

- A. data owner.
- B. security administrator.

- C. IT security manager.
- D. requestor's immediate supervisor.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

When a business application is developed, the best practice is to assign an information or data owner to the application. The Information owner should be responsible for authorizing access to the application itself or to back-end databases for queries. Choices B and C are not correct because the security administrator and manager normally do not have responsibility for authorizing access to business applications. The requestor's immediate supervisor may share the responsibility for approving user access to a business application system; however, the final responsibility should go to the information owner.

QUESTION 530

An organization has created a policy that defines the types of web sites that users are forbidden to access. What is the MOST effective technology to enforce this policy?

- A. Stateful inspection firewall
- B. Web content filter
- C. Web cache server
- D. Proxy server

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A web content filter accepts or denies web communications according to the configured rules. To help the administrator properly configure the tool, organizations and vendors have made available URL blacklists and classifications for millions of web sites. A stateful inspection firewall is of little help in filtering web traffic since it does not review the content of the web site nor does it take into consideration the sites classification. A web cache server is designed to improve the speed of retrieving the most common or recently visited web pages. A proxy server is incorrect because a proxy server is a server which services the request of its clients by forwarding requests to other servers. Many people incorrectly use proxy server as a synonym of web proxy server even though not all web proxy servers have content filtering capabilities.

QUESTION 531

What would be the MOST effective control for enforcing accountability among database users accessing sensitive information?

- A. implement a log management process
- B. implement a two-factor authentication
- C. Use table views to access sensitive data
- D. Separate database and application servers

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Accountability means knowing what is being done by whom. The best way to enforce the principle is to implement a log management process that would create and store logs with pertinent information such as user name, type of transaction and hour. Choice B, implementing a two- factor authentication, and choice C, using table views to access sensitive data, are controls that would limit access to the database to authorized users but would not resolve the accountability problem. Choice D may help in a better administration or even in implementing access controls but, again, does not address the accountability issues.

QUESTION 532

Which of the following intrusion detection systems (IDSs) monitors the general patterns of activity and traffic on a network and creates a database?

- A. Signature-based
- B. Neural networks-based
- C. Statistical-based
- D. Host-based

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The neural networks-based IDS monitors the general patterns of activity and traffic on the network and creates a database. This is similar to the statistical model but has the added function of self-learning. Signature-based systems are a type of IDS in which the intrusive patterns identified are stored in the form of signatures. These IDS systems protect against detected intrusion patterns. Statistical-based systems need a comprehensive definition of the known and expected behavior of systems. Host-based systems are not a type of IDS, but a category of IDS, and are configured for a specific environment. They will monitor various internal resources of the operating system to warn of a possible attack.

QUESTION 533

The MOST important difference between hashing and encryption is that hashing:

- A. is irreversible.
- B. output is the same length as the original message.
- C. is concerned with integrity and security.
- D. is the same at the sending and receiving end.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Hashing works one way; by applying a hashing algorithm to a message, a message hash/digest is created. If the same hashing algorithm is applied to the message digest, it will not result in the original message. As such,

hashing is irreversible, while encryption is reversible. This is the basic difference between hashing and encryption. Hashing creates an output that is smaller than the original message, and encryption creates an output of the same length as the original message. Hashing is used to verify the integrity of the message and does not address security. The same hashing algorithm is used at the sending and receiving ends to generate and verify the message hash/digest. Encryption will

not necessarily use the same algorithm at the sending and receiving and to encrypt and decrypt.

QUESTION 534

Which of the following cryptography options would increase overhead/cost?

- A. The encryption is symmetric rather than asymmetric.
- B. A long asymmetric encryption key is used.
- C. The hash is encrypted rather than the message.
- D. A secret key is used.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Computer processing time is increased for longer asymmetric encryption keys, and the increase may be disproportionate. For example, one benchmark showed that doubling the length of an RSA key from 512 bits to 1,024 bits caused the decrypt time to increase nearly six-fold. An asymmetric algorithm requires more processing time than symmetric algorithms. A hash is shorter than the original message; therefore, a smaller overhead is required if the hash is encrypted rather than the message. Use of a secret key, as a symmetric encryption key, is generally small and used for the purpose of encrypting user data.

QUESTION 535

The MOST important success factor in planning a penetration test is:

- A. the documentation of the planned testing procedure.
- B. scheduling and deciding on the timed length of the test.
- C. the involvement of the management of the client organization.
- D. the qualifications and experience of staff involved in the test.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The most important part of planning any penetration test is the involvement of the management of the client organization. Penetration testing without management approval could reasonably be considered espionage and is illegal in many jurisdictions.

QUESTION 536

Which of the following virus prevention techniques can be implemented through hardware?

- A. Remote booting
- B. Heuristic scanners
- C. Behavior blockers
- D. Immunizers

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Remote booting (e.g., diskless workstations) is a method of preventing viruses, and can be implemented through hardware. Choice C is a detection, not a prevention, although it is hardware-based. Choices B and D are not hardware-based.

QUESTION 537

Which of the following append themselves to files as a protection against viruses?

- A. Behavior blockers
- B. Cyclical redundancy checkers (CRCs)
- C. Immunizers
- D. Active monitors

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Immunizers defend against viruses by appending sections of themselves to files. They continuously check the file for changes and report changes as possible viral behavior. Behavior blockers focus on detecting potentially abnormal behavior, such as writing to the boot sector or the master boot record, or making changes to executable files. Cyclical redundancy checkers compute a binary number on a known virus-free program that is then stored in a database file. When that program is subsequently called to be executed, the checkers look for changes to the files, compare it to the database and report possible infection if changes have occurred. Active monitors interpret DOS and ROM basic input-output system (BIOS) calls, looking for virus-like actions.

QUESTION 538

Which of the following acts as a decoy to detect active internet attacks?

- A. Honey pots
- B. Firewalls
- C. Trapdoors
- D. Traffic analysis

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Honey pots are computer systems that are expressly set up to attract and trap individuals who attempt to penetrate other individuals' computer systems. The concept of a honeypot is to learn from intruder's actions. A properly designed and configured honeypot provides data on methods used to attack systems. The data are then used to improve measures that could curb future attacks. A firewall is basically a preventive measure. Trapdoors create a vulnerability that provides an opportunity for the insertion of unauthorized code into a system. Traffic analysis is a type of passive attack.

QUESTION 539

A certificate authority (CA) can delegate the processes of:

- A. revocation and suspension of a subscriber's certificate.
- B. generation and distribution of the CA public key.
- C. establishing a link between the requesting entity and its public key.
- D. issuing and distributing subscriber certificates.,

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Establishing a link between the requesting entity and its public key is a function of a registration authority. This may or may not be performed by a CA; therefore, this function can be delegated. Revocation and suspension and issuance and distribution of the subscriber certificate are functions of the subscriber certificate life cycle management, which the CA must perform.

Generation and distribution of the CA public key is a part of the CA key life cycle management process and, as such, cannot be delegated.

QUESTION 540

Which of the following results in a denial-of-service attack?

- A. Brute force attack
- B. Ping of death
- C. Leapfrog attack
- D. Negative acknowledgement (NAK) attack

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The use of Ping with a packet size higher than 65 KB and no fragmentation flag on will cause a denial of service. A brute force attack is typically a text attack that exhausts all possible key combinations. A leapfrog attack, the act of tenting through one or more hosts to preclude a trace, makes use of user ID and password information obtained illicitly from one host to compromise another host. A negative acknowledgement attack is a penetration technique that capitalizes on a potential weakness in an operating system that does not handle asynchronous interrupts properly, leaving the system in an unprotected state during such interrupts.

QUESTION 541

Which of the following is the GREATEST advantage of elliptic curve encryption over RSA encryption?

- A. Computation speed
- B. Ability to support digital signatures
- C. Simpler key distribution
- D. Greater strength for a given key length

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The main advantage of elliptic curve encryption over RSA encryption is its computation speed. This method was first independently suggested by Neal Koblitz and Victor S. Miller. Both encryption methods support digital signatures and are used for public key encryption and distribution. However, a stronger key per se does not necessarily guarantee better performance, but rather the actual algorithm employed.

QUESTION 542

Which of the following would be the BEST overall control for an Internet business looking for confidentiality, reliability and integrity of data?

- A. Secure Sockets Layer (SSL)
- B. Intrusion detection system (IDS)
- C. Public key infrastructure (PKI)
- D. Virtual private network (VPN)

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

PKI would be the best overall technology because cryptography provides for encryption, digital signatures and non-repudiation controls for confidentiality and reliability. SSL can provide confidentiality. IDS is a detective control. A VPN would provide confidentiality and authentication (reliability).

QUESTION 543

To ensure message integrity, confidentiality and non-repudiation between two parties, the MOST effective method would be to create a message digest by applying a cryptographic hashing algorithm against:

- A. the entire message, enciphering the message digest using the sender's private key, enciphering the message with a symmetric key and enciphering the key by using the receiver's public key.
- B. any part of the message, enciphering the message digest using the sender's private key, enciphering the message with a symmetric key and enciphering the key using the receiver's public key.
- C. the entire message, enciphering the message digest using the sender's private key, enciphering the message with a symmetric key and enciphering both the encrypted message and digest using the receiver's public key.
- D. the entire message, enciphering the message digest using the sender's private key and enciphering the message using the receiver's public key.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Applying a cryptographic hashing algorithm against the entire message addresses the message integrity issue. Enciphering the message digest using the sender's private key addresses non repudiation. Encrypting the message with a symmetric key, thereafter allowing the key to be enciphered using the receiver's public key,

most efficiently addresses the confidentiality of the message as well as the receiver's non repudiation. The other choices would address only a portion of the requirements.

QUESTION 544

Which of the following antivirus software implementation strategies would be the MOST effective in an interconnected corporate network?

- A. Server antivirus software
- B. Virus walls
- C. Workstation antivirus software
- D. Virus signature updating

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An important means of controlling the spread of viruses is to detect the virus at the point of entry, before it has an opportunity to cause damage. In an interconnected corporate network, virus scanning software, used as an integral part of firewall technologies, is referred to as a virus wall. Virus walls scan incoming traffic with the intent of detecting and removing viruses before they enter the protected network. The presence of virus walls does not preclude the necessity for installing virus detection software on servers and workstations within the network, but network-level protection is most effective the earlier the virus is detected. Virus signature updating is a must in all circumstances, networked or not.

QUESTION 545

Which of the following would be of MOST concern to an IS auditor reviewing a virtual private network (VPN) implementation? Computers on the network that are located:

- A. on the enterprise's internal network.
- B. at the backup site.
- C. in employees' homes.
- D. at the enterprise's remote offices.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

One risk of a virtual private network (VPN) implementation is the chance of allowing high-risk computers onto the enterprise's network. All machines that are allowed onto the virtual network should be subject to the same security policy. Home computers are least subject to the corporate security policies, and therefore are high-risk computers. Once a computer is hacked and 'owned' any network that trusts that computer is at risk. Implementation and adherence to corporate security policy is easier when all computers on the network are on the enterprise's campus. On an enterprise's internal network, there should be security policies in place to detect and halt an outside attack that uses an internal machine as a staging platform. Computers at the backup site are subject to the corporate security policy, and therefore are not high-risk computers. Computers on the network that are at the enterprise's remote offices, perhaps with different IS and security employees who have different ideas about security, are more risky than choices A and B, but obviously less risky than home computers.

QUESTION 546

The PRIMARY reason for using digital signatures is to ensure data:

- A. confidentiality.
- B. integrity.
- C. availability.
- D. timeliness.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Digital signatures provide integrity because the digital signature of a signed message (file, mail, document, etc.) changes every time a single bit of the document changes; thus, a signed document cannot be altered. Depending on the mechanism chosen to implement a digital signature, the mechanism might be able to ensure data confidentiality or even timeliness, but this is not assured. Availability is not related to digital signatures.

QUESTION 547

Which of the following is an example of a passive attack initiated through the Internet?

- A. Traffic analysis
- B. Masquerading
- C. Denial of service
- D. E-mail spoofing

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Internet security threats/vulnerabilities are divided into passive and active attacks. Examples of passive attacks include network analysis, eavesdropping and traffic analysis. Active attacks include brute force attacks, masquerading, packet replay, message modification, unauthorized access through the Internet or web-based services, denial-of-service attacks, dial-in penetration attacks, e-mail bombing and spamming, and e-mail spoofing.

QUESTION 548

Transmitting redundant information with each character or frame to facilitate detection and correction of errors is called a:

- A. feedback error control.
- B. block sum check.
- C. forward error control.
- D. cyclic redundancy check.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Forward error control involves transmitting additional redundant information with each character or frame to facilitate detection and correction of errors, in feedback error control, only enough additional information is transmitted so the receiver can identify that an error has occurred. Choices B and D are both error detection methods but not error correction methods. Block sum check is an extension of parity check wherein an additional set of parity bits is computed for a block of characters. A cyclic redundancy check is a technique wherein a single set of check digits is generated, based on the contents of the frame, for each frame transmitted.

QUESTION 549

The security level of a private key system depends on the number of:

- A. encryption key bits.
- B. messages sent.
- C. keys.
- D. channels used.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The security level of a private key system depends on the number of encryption key bits. The larger the number of bits, the more difficult it would be to understand or determine the algorithm. The security of the message will depend on the encryption key bits used. More than keys by themselves, the algorithm and its complexity make the content more secured. Channels, which could be open or secure, are the mode for sending the message.

QUESTION 550

During what process should router access control lists be reviewed?

- A. Environmental review
- B. Network security review
- C. Business continuity review
- D. Data integrity review

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Network security reviews include reviewing router access control lists, port scanning, internal and external connections to the system, etc. Environmental reviews, business continuity reviews and data integrity reviews do not require a review of the router access control lists.

QUESTION 551

Which of the following components is responsible for the collection of data in an intrusion detection system (IDS)?

- A. Analyzer
- B. Administration console
- C. User interface
- D. Sensor

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Sensors are responsible for collecting data. Analyzers receive input from sensors and determine intrusive activity. An administration console and a user interface are components of an IDS.

QUESTION 552

Which of the following concerns associated with the World Wide Web would be addressed by a firewall?

- A. Unauthorized access from outside the organization
- B. Unauthorized access from within the organization
- C. A delay in Internet connectivity
- D. A delay in downloading using File Transfer Protocol (FTP)

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Firewalls are meant to prevent outsiders from gaining access to an organization's computer systems through the internet gateway. They form a barrier with the outside world, but are not intended to address access by internal users; they are more likely to cause delays than address such concerns.

QUESTION 553

A digital signature contains a message digest to:

- A. show if the message has been altered after transmission.
- B. define the encryption algorithm.
- C. confirm the identity of the originator.
- D. enable message transmission in a digital format.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The message digest is calculated and included in a digital signature to prove that the message has not been altered. It should be the same value as a recalculation performed upon receipt. It does not define the algorithm or enable the transmission in digital format and has no effect on the identity of the user; it is there to ensure integrity rather than identity.

QUESTION 554

Which of the following manages the digital certificate life cycle to ensure adequate security and controls exist in digital signature applications related to e-commerce?

- A. Registration authority
- B. Certificate authority (CA)
- C. Certification relocation list
- D. Certification practice statement

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The certificate authority maintains a directory of digital certificates for the reference of those receiving them, it manages the certificate life cycle, including certificate directory maintenance and certificate revocation list maintenance and publication. Choice A is not correct because a registration authority is an optional entity that is responsible for the administrative tasks associated with registering the end entity that is the subject of the certificate issued by the CA. Choice C is incorrect since a CRL is an instrument for checking the continued validity of the certificates for which the CA has responsibility. Choice D is incorrect because a certification practice statement is a detailed set of rules governing the certificate authority's operations.

QUESTION 555

A TCP/IP-based environment is exposed to the Internet. Which of the following BEST ensures that complete encryption and authentication protocols exist for protecting information while transmitted?

- A. Work is completed in tunnel mode with IP security using the nested services of authentication header (AH) and encapsulating security payload (ESP).
- B. A digital signature with RSA has been implemented.
- C. Digital certificates with RSA are being used.
- D. Work is being completed in TCP services.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Tunnel mode with IP security provides encryption and authentication of the complete IP package. To accomplish this, the AH and ESP services can be nested. Choices B and C provide authentication and integrity. TCP services do not provide encryption and authentication.

QUESTION 556

Digital signatures require the:

- A. signer to have a public key and the receiver to have a private key.
- B. signer to have a private key and the receiver to have a public key.
- C. signer and receiver to have a public key.
- D. signer and receiver to have a private key.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Digital signatures are intended to verify to a recipient the integrity of the data and the identity of the sender. The digital signature standard is a public key algorithm. This requires the signer to have a private key and the receiver to have a public key.

QUESTION 557

The feature of a digital signature that ensures the sender cannot later deny generating and sending the message is called:

- A. data integrity.
- B. authentication.
- C. non repudiation.
- D. replay protection.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

All of the above are features of a digital signature. Non repudiation ensures that the claimed sender cannot later deny generating and sending the message. Data integrity refers to changes in the plaintext message that would result in the recipient failing to compute the same message hash. Since only the claimed sender has the key, authentication ensures that the message has been sent by the claimed sender. Replay protection is a method that a recipient can use to check that the message was not intercepted and replayed.

QUESTION 558

An IS auditor doing penetration testing during an audit of internet connections would:

- A. evaluate configurations.
- B. examine security settings.
- C. ensure virus-scanning software is in use.
- D. use tools and techniques available to a hacker.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Penetration testing is a technique used to mimic an experienced hacker attacking a live site by using tools and techniques available to a hacker. The other choices are procedures that an IS auditor would consider undertaking during an audit of Internet connections, but are not aspects of penetration testing techniques.

QUESTION 559

Which of the following should concern an IS auditor when reviewing security in a client-server environment?

- A. Protecting data using an encryption technique
- B. Preventing unauthorized access using a diskless workstation
- C. The ability of users to access and modify the database directly
- D. Disabling floppy drives on the users' machines

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

For the purpose of data security in a client-server environment, an IS auditor should be concerned with the user's ability to access and modify a database directly. This could affect the integrity of the data in the database. Data protected by encryption aid in securing the data. Diskless workstations prevent copying of data into local disks and thus help to maintain the integrity and confidentiality of data. Disabling floppy drives is a physical access control, which helps to maintain the confidentiality of data by preventing it from being copied onto a disk.

QUESTION 560

Which of the following is a technique that could be used to capture network user passwords?

- A. Encryption
- B. Sniffing
- C. Spoofing
- D. Data destruction

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: Sniffing is an attack that can be used to capture sensitive pieces of information (e.g., a password) passing through the network. Encryption is a method of scrambling information to prevent unauthorized individuals from understanding the transmission. Spoofing is forging an address and inserting it into a packet to disguise the origin of the communication. Data destruction is erasing information or removing it from its original location.

QUESTION 561

Which of the following controls would BEST detect intrusion?

- A. User IDs and user privileges are granted through authorized procedures.
- B. Automatic logoff is used when a workstation is inactive for a particular period of time.
- C. Automatic logoff of the system occurs after a specified number of unsuccessful attempts.
- D. Unsuccessful logon attempts are monitored by the security administrator.

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Intrusion is detected by the active monitoring and review of unsuccessful logons. User IDs and the granting of user privileges define a policy, not a control. Automatic logoff is a method of preventing access on inactive terminals and is not a detective control. Unsuccessful attempts to log on are a method for preventing intrusion, not detecting.

QUESTION 562

Which of the following is a feature of an intrusion detection system (IDS)?

- A. Gathering evidence on attack attempts
- B. Identifying weaknesses in the policy definition
- C. Blocking access to particular sites on the Internet
- D. Preventing certain users from accessing specific servers

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

An IDS can gather evidence on intrusive activity such as an attack or penetration attempt. Identifying weaknesses in the policy definition is a limitation of an IDS. Choices C and D are features of firewalls, while choice B requires a manual review, and therefore is outside the functionality of an IDS.

QUESTION 563

An IS auditor performing a telecommunication access control review should be concerned PRIMARILY with the:

- A. maintenance of access logs of usage of various system resources.
- B. authorization and authentication of the user prior to granting access to system resources.
- C. adequate protection of stored data on servers by encryption or other means.
- D. accountability system and the ability to identify any terminal accessing system resources.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The authorization and authentication of users is the most significant aspect in a telecommunications access control review, as it is a preventive control. Weak controls at this level can affect all other aspects. The maintenance of access logs of usage of system resources is a detective control. The adequate protection of data being transmitted to and from servers by encryption or other means is a method of protecting information during transmission and is not an access issue. The accountability system and the ability to identify any terminal accessing system resources deal with controlling access through the identification of a terminal.

QUESTION 564

Which of the following is the MOST effective type of antivirus software?

- A. Scanners

- B. Active monitors
- C. integrity checkers
- D. Vaccines

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Integrity checkers compute a binary number on a known virus-free program that is then stored in a database file. This number is called a cyclical redundancy check (CRC). When that program is called to execute, the checker computes the CRC on the program about to be executed and compares it to the number in the database. A match means no infection; a mismatch means that a change in the program has occurred. A change in the program could mean a virus. Scanners look for sequences of bits called signatures that are typical of virus programs. They examine memory, disk boot sectors, executables and command files for bit patterns that match a known virus. Therefore, scanners need to be updated periodically to remain effective. Active monitors interpret DOS and ROM basic input-output system (BIOS) calls, looking for virus-like actions. Active monitors can be misleading, because they cannot distinguish between a user request and a program or virus request. As a result, users are asked to confirm actions like formatting a disk or deleting a file or set of files. Vaccines are known to be good antivirus software. However, they also need to be updated periodically to remain effective.

QUESTION 565

When using public key encryption to secure data being transmitted across a network:

- A. both the key used to encrypt and decrypt the data are public.
- B. the key used to encrypt is private, but the key used to decrypt the data is public.
- C. the key used to encrypt is public, but the key used to decrypt the data is private.
- D. both the key used to encrypt and decrypt the data are private.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Public key encryption, also known as asymmetric key cryptography, uses a public key to encrypt the message and a private key to decrypt it.

QUESTION 566

The technique used to ensure security in virtual private networks (VPNs) is:

- A. encapsulation.
- B. wrapping.
- C. transform.
- D. encryption

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Encapsulation, or tunneling, is a technique used to carry the traffic of one protocol over a network that does not support that protocol directly. The original packet is wrapped in another packet. The other choices are not security techniques specific to VPNs.

QUESTION 567

During an audit of a telecommunications system, an IS auditor finds that the risk of intercepting data transmitted to and from remote sites is very high. The MOST effective control for reducing this exposure is:

- A. encryption.
- B. callback modems.
- C. message authentication.
- D. dedicated leased lines.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Encryption of data is the most secure method. The other methods are less secure, with leased lines being possibly the least secure method.

QUESTION 568

An internet-based attack using password sniffing can:

- A. enable one party to act as if they are another party.
- B. cause modification to the contents of certain transactions.
- C. be used to gain access to systems containing proprietary information.
- D. result in major problems with billing systems and transaction processing agreements.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Password sniffing attacks can be used to gain access to systems on which proprietary information is stored. Spoofing attacks can be used to enable one party to act as if they are another party. Data modification attacks can be used to modify the contents of certain transactions. Repudiation of transactions can cause major problems with billing systems and transaction processing agreements.

QUESTION 569

Which of the following controls would be the MOST comprehensive in a remote access network with multiple and diverse subsystems?

- A. Proxy server
- B. Firewall installation
- C. Network administrator

D. Password implementation and administration

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The most comprehensive control in this situation is password implementation and administration. While firewall installations are the primary line of defense, they cannot protect all access and, therefore, an element of risk remains. A proxy server is a type of firewall installation; thus, the same rules apply. The network administrator may serve as a control, but typically this would not be comprehensive enough to serve on multiple and diverse systems.

QUESTION 570

During an audit of an enterprise that is dedicated to e-commerce, the IS manager states that digital signatures are used when receiving communications from customers. To substantiate this, an IS auditor must prove that which of the following is used?

- A. A biometric, digitalized and encrypted parameter with the customer's public key
- B. A hash of the data that is transmitted and encrypted with the customer's private key
- C. A hash of the data that is transmitted and encrypted with the customer's public key
- D. The customer's scanned signature encrypted with the customer's public key

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The calculation of a hash, or digest, of the data that are transmitted and its encryption require the public key of the client (receiver) and is called a signature of the message, or digital signature. The receiver performs the same process and then compares the received hash, once it has been decrypted with their private key, to the hash that is calculated with the received data. If they are the same, the conclusion would be that there is integrity in the data that have arrived and the origin is authenticated. The concept of encrypting the hash with the private key of the originator provides non repudiation, as it can only be decrypted with their public key and, as the CD suggests, the private key would not be known to the recipient. Simply put, in a key-pair situation, anything that can be decrypted by a sender's public key must have been encrypted with their private key, so they must have been the sender, i.e., non-repudiation. Choice C is incorrect because, if this were the case, the hash could not be decrypted by the recipient, so the benefit of non-repudiation would be lost and there could be no verification that the message had not been intercepted and amended. A digital signature is created by encrypting with a private key. A person creating the signature uses their own private key, otherwise everyone would be able to create a signature with any public key. Therefore, the signature of the client is created with the client's private key, and this can be verified--by the enterprise--using the client's public key. Choice B is the correct answer because, in this case, the customer uses their private key to sign the hash data.

QUESTION 571

When planning an audit of a network setup, an IS auditor should give highest priority to obtaining which of the following network documentation?

- A. Wiring and schematic diagram
- B. Users' lists and responsibilities
- C. Application lists and their details
- D. Backup and recovery procedures

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The wiring and schematic diagram of the network is necessary to carry out a network audit. A network audit

may not be feasible if a network wiring and schematic diagram is not available. All other documents are important but not necessary.

QUESTION 572

Which of the following encrypt/decrypt steps provides the GREATEST assurance of achieving confidentiality, message integrity and nonrepudiation by either sender or recipient?

- A. The recipient uses their private key to decrypt the secret key.
- B. The encrypted prehash code and the message are encrypted using a secret key.
- C. The encrypted prehash code is derived mathematically from the message to be sent.
- D. The recipient uses the sender's public key, verified with a certificate authority, to decrypt the prehash code.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Most encrypted transactions use a combination of private keys, public keys, secret keys, hash functions and digital certificates to achieve confidentiality, message integrity and nonrepudiation by either sender or recipient. The recipient uses the sender's public key to decrypt the prehash code into a posthash code, which when equaling the prehash code, verifies the identity of the sender and that the message has not been changed in route; this would provide the greatest assurance. Each sender and recipient has a private key known only to themselves and a public key, which can be known by anyone. Each encryption/decryption process requires at least one public key and one private key, and both must be from the same party. A single, secret key is used to encrypt the message, because secret key encryption requires less processing power than using public and private keys. A digital certificate, signed by a certificate authority, validates senders' and recipients' public keys.

QUESTION 573

Use of asymmetric encryption in an internet e-commerce site, where there is one private key for the hosting server and the public key is widely distributed to the customers, is MOST likely to provide comfort to the:

- A. customer over the authenticity of the hosting organization.
- B. hosting organization over the authenticity of the customer.
- C. customer over the confidentiality of messages from the hosting organization.
- D. hosting organization over the confidentiality of messages passed to the customer.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Any false site will not be able to encrypt using the private key of the real site, so the customer would not be able to decrypt the message using the public key. Many customers have access to the same public key so the host cannot use this mechanism to ensure the authenticity of the customer. The customer cannot be assured of the confidentiality of messages from the host as many people have access to the public key and can decrypt the messages from the host. The host cannot be assured of the confidentiality of messages sent out, as many people have access to the public key and can decrypt it.

QUESTION 574

E-mail message authenticity and confidentiality is BEST achieved by signing the message using the:

- A. sender's private key and encrypting the message using the receiver's public key.
- B. sender's public key and encrypting the message using the receiver's private key.
- C. receiver's private key and encrypting the message using the sender's public key.
- D. receiver's public key and encrypting the message using the sender's private key.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

By signing the message with the sender's private key, the receiver can verify its authenticity using the sender's public key. By encrypting the message with the receiver's public key, only the receiver can decrypt the message using their own private key. The receiver's private key is confidential and, therefore, unknown to the sender. Messages encrypted using the sender's private key can be read by anyone with the sender's public key.

QUESTION 575

An organization is considering connecting a critical PC-based system to the Internet. Which of the following would provide the BEST protection against hacking?

- A. An application-level gateway
- B. A remote access server
- C. A proxy server
- D. Port scanning

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An application-level gateway is the best way to protect against hacking because it can define with detail rules that describe the type of user or connection that is or is not permitted, it analyzes in detail each package, not only in layers one through four of the OSI model but also layers five through seven, which means that it reviews the commands of each higher-level protocol (HTTP, FTP, SNMP, etc.). For a remote access server, there is a device (server) that asks for a username and password before entering the network. This is good when accessing private networks, but it can be mapped or scanned from the Internet creating security exposure. Proxy servers can provide protection based on the IP address and ports. However, an individual is needed who really knows how to do this, and applications can use different ports for the different sections of the program. Port scanning works when there is a very specific task to complete, but not when trying to control what comes from the Internet, or when all the ports available need to be controlled. For example, the port for Ping (echo request) could be blocked and the IP addresses would be available for the application and browsing, but would not respond to Ping.

QUESTION 576

Which of the following is the MOST secure and economical method for connecting a private network over the Internet in a small- to medium-sized organization?

- A. Virtual private network
- B. Dedicated line
- C. Leased line
- D. integrated services digital network

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The most secure method is a virtual private network (VPN), using encryption, authentication and tunneling to allow data to travel securely from a private network to the internet. Choices B, C and D are network connectivity options that are normally too expensive to be practical for small- to medium-sized organizations.

QUESTION 577

The potential for unauthorized system access by way of terminals or workstations within an organization's facility is increased when:

- A. connecting points are available in the facility to connect laptops to the network.
- B. users take precautions to keep their passwords confidential.
- C. terminals with password protection are located in insecure locations.
- D. terminals are located within the facility in small clusters under the supervision of an administrator.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Any person with wrongful intentions can connect a laptop to the network. The insecure connecting points, make unauthorized access possible if the individual has knowledge of a valid user ID and password. The other choices are controls for preventing unauthorized network access. If system passwords are not readily available for intruders to use, they must guess, introducing an additional factor and requires time. System passwords provide protection against unauthorized use of terminals located in insecure locations. Supervision is a very effective control when used to monitor access to a small operating unit or production resources.

QUESTION 578

Which of the following functions is performed by a virtual private network (VPN)?

- A. Hiding information from sniffers on the net
- B. Enforcing security policies
- C. Detecting misuse or mistakes
- D. Regulating access

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A VPN hides information from sniffers on the net using encryption. It works based on tunneling. A VPN does not analyze information packets and, therefore, cannot enforce security policies; it also does not check the content of packets, so it cannot detect misuse or mistakes. A VPN also does not perform an authentication function and, therefore, cannot regulate access.

QUESTION 579

An IS auditor is reviewing an organization's information asset management process. Which of the following would be of GREATEST concern to the auditor?

- A. Process ownership has not been established.
- B. Identification of asset value is not included in the process.
- C. The process does not require specifying the physical locations of assets.
- D. The process does not include asset review.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 580

Which of the following should be considered the MOST important factor when evaluating the level of protection of fireproof magnetic media containers?

- A. Storage location of the containers with respect to flammable material
- B. Peak temperature and humidity of the storage location
- C. Peak temperature and humidity ratings inside the container
- D. Resistance of the container to water, Halon, and carbon dioxide

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 581

Which of the following would BEST protect a network from a worm that exploits a publicly announced operating system vulnerability?

- A. Antivirus software
- B. User awareness and training
- C. Host security
- D. Patch management

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 582

Which of the following is the MOST effective control for protecting the confidentiality and integrity of data stored unencrypted on virtual machines?

- A. Monitor access to stored images and snapshots of virtual machines
- B. Restrict access to images and snapshots of virtual machines
- C. Review logical access controls on virtual machines regularly
- D. Limit creation of virtual machine images and snapshots

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 583

What is the MAIN objective when implementing security controls within an application?

- A. To minimize reputational risk to the organization
- B. To minimize the exposure to the fullest extent possible
- C. To optimize the level of data protection achieved against cost
- D. To optimize user functionality of the application

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 584

Which of the following controls would BEST help to protect an organization from social engineering attacks?

- A. Email monitoring
- B. Social media access restrictions
- C. Security awareness training
- D. Firewall access control list reviews

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 585

What is the PRIMARY reason for including a clause requiring source code escrow in an application vendor agreement?

- A. Protect the organization from copyright disputes.
- B. Ensure source code changes are recorded.
- C. Segregate system development and live environments.
- D. Ensure the source code remains available.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 586

Which of the following would provide the BEST evidence of the adequacy of firewall rules?

- A. Performing penetration tests
- B. Reviewing intrusion detection system (IDS) logs
- C. Reviewing network logs
- D. Verifying firewall configuration

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 587

Which of the following is the BEST control to reduce the likelihood that a spear phishing attack will be successful?

- A. Tools for users to report suspicious emails and unusual financial transactions
- B. Spam filtering for emails containing external hyperlinks sent to mass recipient lists
- C. Automated alerts to security managers identifying confidential information transferred externally
- D. Education for staff and high-profile users on social engineering

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 588

Which of the following would BEST help management maintain a current and effective business continuity plan (BCP)?

- A. Update the critical business software list on an annual basis.
- B. Perform a periodic recovery test and include a lessons-learned summary.
- C. Perform an annual walk-through and verify resources at the recovery site.
- D. Verify vendor restore requirements are consistent with the recovery plan.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 589

An IS auditor is reviewing environmental controls and finds extremely high levels of humidity in the data center. Which of the following is the PRIMARY risk to computer equipment from this condition?

- A. Brownout
- B. Fire
- C. Static electricity
- D. Corrosion

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 590

Which of the following is the BEST way to minimize the impact of a ransomware attack?

- A. Grant system access based on least privilege.
- B. Provide user awareness training on ransomware attacks.
- C. Perform more frequent system backups.
- D. Maintain a regular schedule for patch updates.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 591

What is the BEST type of network topology to reduce the risk of network faults?

- A. Bus network
- B. Star network
- C. Ring network
- D. Mesh network

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 592

An organization's sensitive data is stored in a cloud computing environment and is encrypted. Which of the following findings should be of GREATEST concern to an IS auditor?

- A. Symmetric keys are used for encryption.
- B. Encryption keys are not rotated on a regular basis.
- C. Test data encryption keys are being used in production.
- D. Data encryption keys are accessible to the service provider.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 593

Which of the following is the MOST important metric in selecting a biometric device?

- A. System response time
- B. Crossover error rate
- C. False rejection rate
- D. Image size

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 594

An IS auditor observes that a bank's web page address is prefixed "https://". The auditor would be correct to conclude that:

- A. the bank has a restricted Internet protocol (IP) address.
- B. the bank has established a virtual private network (VPN).
- C. the customer is connected to the bank's intranet.
- D. transactions are encrypted.

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 595

When a data center is attempting to restore computing facilities at an alternative site following a disaster, which of the following should be restored FIRST?

- A. Data backups
- B. Decision support system
- C. Operating system
- D. Applications

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 596

Which of the following findings would be of GREATEST concern when reviewing a business impact analysis (BIA)?

- A. There is not adequate documentation to perform a recovery.
- B. The business continuity plan (BCP) does not align with corporate strategy.
- C. Several key business processes were not included.
- D. The recovery point objective (RPO) is not accurate.

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 597

Which of the following would BEST detect unauthorized modification of data by a database administrator (DBA)?

- A. Audit database change requests
- B. Audit database activity logs
- C. Review changes to edit checks
- D. Compare data to input records

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 598

Which of the following attacks would MOST likely result in the interception and modification of traffic for mobile phones connecting to potentially insecure public Wi-Fi networks?

- A. Phishing
- B. Man-in-the middle
- C. Vishing
- D. Brute force

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 599

An IS auditor is reviewing a small organization's business continuity and disaster recovery plans. Which of the following findings would pose the GREATEST concern?

- A. Data backup and storage is not performed every day.
- B. Practice drills related to the plans are conducted infrequently.
- C. The plans are not periodically reviewed and updated.
- D. The organization's hardware is near end-of-life.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 600

Which of the following is the BEST method to delete sensitive information from storage media that will be reused?

- A. Multiple-overwriting
- B. Crypto-shredding
- C. Reformatting
- D. Re-partitioning

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 601

Which of the following processes would benefit MOST from vulnerability scan results?

- A. Traffic management
- B. Patch management
- C. Asset management
- D. Incident management

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 602

The use of cookies constitutes the MOST significant security threat when they are used for:

- A. authenticating using username and password.
- B. downloading files from the host server.
- C. obtaining a public key from a certification authority (CA).
- D. forwarding email and Internet protocol (IP) addresses.

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 603

Which of the following is the BEST control to help prevent sensitive data leaving an organization via email?

- A. Scanning outgoing emails
- B. Providing encryption solutions for employees
- C. Conducting periodic phishing tests
- D. Blocking outbound emails sent without encryption

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 604

A manager identifies active privileged accounts belonging to staff who have left the organization. Which of the following is the threat actor in this scenario?

- A. Hacktivists
- B. Deleted log data
- C. Terminated staff
- D. Unauthorized access

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 605

Which of the following BEST help to ensure system resiliency for a business application that processes high- volume and real-time retail transactions?

- A. Adequate resourcing for the incident response team
- B. Adequate encryption between applications
- C. Adequate application clustering
- D. Adequate reciprocal recovery agreement

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 606

The PRIMARY purpose of conducting a test of an alternate site as part of a disaster recovery program is to:

- A. assess security awareness among employees.
- B. determine recovery time objectives (RTOs).
- C. verify the alternate infrastructure works as designed.
- D. identify hidden costs for maintaining the site.

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 607

Which of the following is the BEST method to secure credit card information displayed by an application used by both customer service representatives and fraud analysts?

- A. Truncation
- B. One-way hash
- C. Encryption
- D. Masking

Correct Answer: C
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 608

Which of the following types of environmental equipment will MOST likely be deployed below the floor tiles of a data center?

- A. Temperature sensors
- B. Air pressure sensors
- C. Humidity sensors
- D. Water sensors

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 609

An IS auditor is evaluating the risk of zero-day attacks and related mitigating controls for an organization. The auditor's BEST recommendation is to implement:

- A. a demilitarized zone (DMZ).
- B. a signature-based antivirus program.

- C. a heuristic intrusion prevention system (IPS).
- D. an intrusion detection system (IDS).

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 610

What is the MOST important consideration of any disaster response plan?

- A. Personnel safety
- B. Business resumption
- C. Adequate resource capacity
- D. IT asset protection

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 611

The practice of performing backups reflects which type of internal control?

- A. Corrective
- B. Preventive
- C. Detective
- D. Compensating

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 612

Which of the following user actions constitutes the GREATEST risk for introducing viruses into a local network?

- A. Downloading a file from an external server
- B. Uploading a file onto an internal server
- C. Opening an email attachment
- D. Viewing a hypertext markup language (HTML) document

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 613

An organization is evaluating a disaster recovery testing scenario in which a ransomware attack occurs and the business impact analysis (BIA) indicates the recovery point objective (RPO) is 6 hours. Which of the following BEST ensures the most recent good data set will be available after the attack occurs?

- A. Replication occurs every 15 minutes.
- B. Backup is configured every 5 hours.
- C. Replication is every 6 hours.
- D. Backup is configured every 4 hours.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 614

Which of the following is a benefit of using symmetric cryptography instead of asymmetric cryptography?

- A. Can be used for digital signature
- B. Efficiency of use
- C. Enhanced authentication
- D. Improved key management

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 615

An external attacker spoofing an internal protocol (IP) address can BEST be detected by which of the following?

- A. Using a state table to compare the message states of each packet as it enters the system
- B. Comparing the source address to the interface used as the entry point
- C. Using static IP addresses for identification
- D. Comparing the source address to the domain name server entry

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 616

During an IT operations audit, multiple unencrypted backup tapes containing sensitive credit card information cannot be found. Which of the following presents the GREATEST risk to the organization?

- A. Reputational damage due to potential identity theft
- B. The cost of recreating the missing backup tapes
- C. Business disruption if a data restore cannot be completed
- D. Human resource cost of responding to the incident

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 617

Tunneling provides additional security for connecting one host to another through the Internet by:

- A. enabling the use of stronger encryption keys.
- B. facilitating the exchange of public key infrastructure (PKI) certificates.
- C. providing end-to-end encryption.
- D. preventing password cracking and replay attacks.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 618

An organization performs both full and incremental database backups. Which of the following will BEST enable full restoration in the event of the destruction of the data center?

- A. Rotate all backups to an offsite location daily.
- B. Transmit incremental backups to an offsite location daily.
- C. Move full backups to an offsite location weekly.
- D. Maintain full and incremental backups in a secure server room.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 619

A new privacy regulation requires a customer's privacy information to be deleted within 72 hours, if requested. Which of the following would be an IS auditor's GREATEST concern regarding compliance to this regulation?

- A. Lack of knowledge of where customers' information is saved
- B. Outdated online privacy policies
- C. Incomplete backup and retention policies
- D. End user access to applications with customer information

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 620

Which of the following clauses is MOST important to include in a contract to help maintain data privacy in the event a Platform as a Service (PaaS) provider becomes financially insolvent?

- A. Secure data destruction
- B. Intellectual property protection
- C. Data classification
- D. Software escrow

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 621

Which of the following BEST guards against the risk of attack by hackers?

- A. Tunneling
- B. Firewalls
- C. Encryption
- D. Message validation

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

<https://www.isaca.org/resources/isaca-journal/issues/2015/volume-5/addressing-cybersecurity-vulnerabilities>

QUESTION 622

Due to a global pandemic, a health organization has instructed its employees to work from home as much as possible. The employees communicate using instant messaging. Which of the following is the GREATEST risk in this situation?

- A. Employee productivity may decrease when working from home.
- B. The capacity of servers may not allow all users to connect simultaneously.
- C. Employees may exchange patient information through less secure methods.
- D. Home office setups may not be compliant with workplace health and safety requirements.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 623

An IS auditor finds that a document related to a client has been leaked. Which of the following should be the auditor's NEXT step?

- A. Notify appropriate law enforcement.
- B. Report data leakage finding to senior management.
- C. Report data leakage finding to regulatory authorities.
- D. Determine the classification of data leaked.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 624

A financial institution is launching a mobile banking service utilizing multi-factor authentication. This access control is an example of which of the following?

- A. Directive control
- B. Detective control
- C. Preventive control
- D. Corrective control

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 625

Which of the following is the BEST way to ensure that business continuity plans (BCPs) will work effectively in the event of a major disaster?

- A. Regularly update business impact assessments.
- B. Make senior managers responsible for their plan sections .
- C. Prepare detailed plans for each business function.
- D. Involve staff at all levels in periodic paper walk-through exercises.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 626

Which of the following is the PRIMARY reason for using a digital signature?

- A. Authenticate the sender of a message
- B. Provide confidentiality to the transmission
- C. Provide availability to the transmission
- D. Verify the integrity of the data and the identity of the recipient

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 627

Which of the following is MOST important to include in a contract to outsource data processing that involves customer personally identifiable information (PII)?

- A. The vendor must provide an independent report of its data processing facilities.
- B. The vendor must sign a nondisclosure agreement (NDA) with the organization.
- C. The vendor must compensate the organization if service levels are not met.
- D. The vendor must comply with the organization's legal and regulatory requirements.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 628

The activation of a pandemic response plan has resulted in a remote workforce situation. Which of the following technologies poses the GREATEST risk to data confidentiality?

- A. Rapid increase in the number of virtual private network (VPN) users
- B. Remotely managed network switches
- C. BYOD devices without adequate endpoint protection
- D. On-premise employee workstations left unattended

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 629

Which of the following techniques would provide the BEST assurance to an IS auditor that all necessary data has been successfully migrated from a legacy system to a modern platform?

- A. Interviews with migration staff
- B. Statistical sampling
- C. Review of logs from the migration process
- D. Data analytics

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 630

Which of the following are examples of detective controls?

- A. Continuity of operations planning and backup procedures
- B. Use of access control software and deploying encryption software
- C. Check points in production jobs and rerun procedures
- D. Source code review and echo checks in telecommunications

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 631

Which of the following is the BEST way to reduce sampling risk?

- A. Align the sampling approach with the one used by external auditors.
- B. Plan the audit in accordance with generally accepted auditing principles.
- C. Assign experienced auditors to the sampling process.
- D. Ensure each item has an equal chance to be selected.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 632

Which of the following would be of GREATEST concern to an IS auditor reviewing backup and recovery controls?

- A. Restores from backups are not periodically tested .
- B. Weekly and monthly backups are stored onsite.
- C. Backup procedures are not documented.
- D. Backups are stored in an external hard drive.

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

<https://www.isaca.org/resources/isaca-journal/issues/2018/volume-1/is-audit-basics-backup-and-recovery>

QUESTION 633

During a database security audit, an IS auditor is reviewing the process used to upload source data. Which of the following is the MOST significant risk area for the auditor to focus on?

- A. Data integrity
- B. Data sensitivity
- C. Data resilience
- D. Data normalization

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 634

Which of the following is the BEST way to ensure payment transaction data is restricted to the appropriate users?

- A. Using a single menu for sensitive application transactions
- B. Restricting access to transactions using network security software
- C. Implementing two-factor authentication
- D. Implementing role-based access at the application level

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 635

Which of the following is the GREATEST advantage of vulnerability scanning over penetration testing?

- A. Custom-developed applications can be tested more accurately.
- B. The testing produces a lower number of false positive results.
- C. The testing process can be automated to cover large groups of assets.
- D. Network bandwidth is utilized more efficiently.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 636

Which of the following statements appearing in an organization's acceptable use policy BEST demonstrates alignment with data classification standards related to the protection of information assets?

- A. Information assets should only be accessed by persons with a justified need
- B. All information assets must be encrypted when stored on the organization's systems
- C. Any information assets transmitted over a public network must be approved by executive management
- D. All information assets will be assigned a clearly defined level to facilitate proper employee handling

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 637

As part of business continuity planning, which of the following is MOST important to assess when conducting a business impact analysis (BIA)?

- A. Risk appetite
- B. Recovery scenarios
- C. Completeness of critical asset inventory
- D. Critical applications in the cloud

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 638

Which of the following is the PRIMARY protocol for protecting outbound content from tampering and eavesdropping?

- A. Transport Layer Security (TLS)
- B. Point-to-Point Protocol (PPP)
- C. Secure Shell (SSH)
- D. Internet Key Exchange (IKE)

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 639

Which of the following would BEST protect the confidentiality of sensitive data in transit between multiple offices?

- A. Public key infrastructure (PKI)
- B. Kerberos
- C. Digital signatures
- D. Hash algorithms

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

QUESTION 640

Which of the following recommendations by an IS auditor is the BEST control to protect an organization's corporate network from the guest wireless network?

- A. Hide the service set identifier (SSID) of the guest network
- B. Place the guest network in its own virtual local area network (LAN)
- C. Authenticate devices connecting to the guest network
- D. Ensure the guest access point is running the latest software

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 641

Critical processes are not defined in an organization's business continuity plan (BCP). Which of the following would have MOST likely identified the gap?

- A. Updating the risk register
- B. Reviewing the business continuity strategy
- C. Reviewing the business impact analysis (BIA)
- D. Testing the incident response plan

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 642

A healthcare facility offers patients health tracking devices that can be monitored remotely by healthcare professionals. Which of the following is the BEST way to protect patient personal information from unauthorized exfiltration?

- A. Restrict the devices to using Internet Protocol (IP) version 6 only
- B. Add a digital certificate to the devices that limits communication to specific servers
- C. Provide the patients with Internet security training and education programs
- D. Configure the devices to reboot automatically every 7 days

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 643

Which of the following is MOST important to ensure when reviewing a global organization's controls to protect data held on its IT infrastructure across all of its locations?

- A. The threat of natural disasters in each location hosting infrastructure has been accounted for.
- B. The capacity of underlying communications infrastructure in the host locations is sufficient.
- C. Technical capabilities exist in each location to manage the data and recovery operations.
- D. Relevant data protection legislation and regulations for each location are adhered to.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 644

Which of the following is the PRIMARY concern when negotiating a contract for a hot site?

- A. Complete testing of the recovery plan
- B. Availability of the site in the event of multiple disaster declarations
- C. Reciprocal agreements with other organizations
- D. Coordination with the site staff in the event of multiple disaster declarations

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 645

Which of the following would an IS auditor recommend as the MOST effective preventive control to reduce the risk of data leakage?

- A. Ensure that paper documents are disposed securely.
- B. Verify that application logs capture any changes made.
- C. Implement an intrusion detection system (IDS).
- D. Validate all data files contain digital watermarks.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 646

During an audit of a disaster recovery plan (DRP) for a critical business area, an IS auditor finds that not all critical systems are covered. What should the auditor do NEXT?

- A. Evaluate the impact of not covering the systems
- B. Escalate the finding to senior management
- C. Evaluate the prior year's audit results regarding critical system coverage
- D. Verify whether the systems are part of the business impact analysis (BIA)

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 647

An organization sends daily backup media by courier to an offsite location. Which of the following provides the BEST evidence that the media is transported reliably?

- A. Documented backup media transport procedures
- B. Certification of the courier company
- C. Deliver schedule of the backup media
- D. Signed acknowledgements by offsite manager

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 648

An organization shares some of its customers' personally identifiable information (PII) with third-party suppliers for business purposes. What is MOST important for the IS auditor to evaluate to ensure that risk associated with leakage of privacy-related data during transmission is effectively managed?

- A. Encrypting and masking of customer data
- B. The third party's privacy and data security policies
- C. Nondisclosure and indemnity agreements
- D. Service and operational level agreements

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 649

Which of the following is the BEST control to mitigate the malware risk associated with an instant messaging (IM) system?

- A. Blocking external IM traffic
- B. Blocking attachments in IM
- C. Allowing only corporate IM solutions
- D. Encrypting IM traffic

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 650

Which of the following types of firewalls provide the GREATEST degree of control against hacker intrusion?

- A. Screening router
- B. Packet filtering router
- C. Application level gateway
- D. Circuit gateway

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 651

Which of the following is the BEST control to prevent the transfer of files to external parties through instant messaging (IM) applications?

- A. File Transfer Protocol (FTP)
- B. Application level firewalls
- C. Instant messaging policy
- D. File level encryption

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 652

Which of the following is MOST effective in detecting an intrusion attempt?

- A. Installing biometrics-based authentication
- B. Analyzing system logs
- C. Using smart cards with one-time passwords
- D. Using packet filter software

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 653

A USB device containing sensitive production data was lost by an employee, and its contents were subsequently found published online. Which of the following controls is the BEST recommendation to prevent a similar recurrence?

- A. Training users on USB device security
- B. Monitoring data being downloaded on USB devices
- C. Electronically tracking portable devices
- D. Using a strong encryption algorithm

Correct Answer: A
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 654

An IS auditor is reviewing an organization's business continuity plan (BCP) following a change in organizational structure with significant impact to business processes. Which of the following findings should be the auditor's GREATEST concern?

- A. Copies of the BCP have not been distributed to new business unit end users since the reorganization
- B. The most recent business impact analysis (BIA) was performed two years before the reorganization
- C. A test plan for the BCP has not been completed during the last two years
- D. Key business process end users did not participate in the business impact analysis (BIA)

Correct Answer: B
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 655

What is BEST for an IS auditor to review when assessing the effectiveness of changes recently made to processes and tools related to an organization's business continuity plan (BCP)?

- A. Change management processes
- B. Completed test plans
- C. Updated inventory of systems
- D. Full test results

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 656

Which type of attack poses the GREATEST risk to an organization's most sensitive data?

- A. Password attack
- B. Eavesdropping attack
- C. Spear phishing attack
- D. Insider attack

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 657

An organization uses multiple offsite data center facilities. Which of the following is MOST important to consider when choosing related backup devices and media?

- A. Associated costs
- B. Standardization
- C. Backup media capacity
- D. Restoration speed

Correct Answer: D
Explanation

Explanation/Reference:
Section: Protection of Information Assets

QUESTION 658

An organization allows employees to retain confidential data on personal mobile devices. Which of the following is the BEST recommendation to mitigate the risk of data leakage from lost or stolen devices?

- A. Require employees to attend security awareness training
- B. Password protect critical data files
- C. Enable device auto-lock function
- D. Configure to auto-wipe after multiple failed access attempts

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 659

Which of the following is the BEST recommendation to prevent fraudulent electronic funds transfers by accounts payable employees?

- A. Re-keying of monetary amounts
- B. Dual control
- C. Periodic vendor reviews
- D. Independent reconciliation

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 660

An IS auditor observes that a business-critical application does not currently have any level of fault tolerance. Which of the following is the GREATEST concern with this situation?

- A. Degradation of services
- B. Limited tolerance for damage
- C. Decreased mean time between failure (MTBF)
- D. Single point of failure

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

QUESTION 661

Applying a digital signature to data traveling in a network provides:

- A. confidentiality and integrity.
- B. security and nonrepudiation.
- C. integrity and nonrepudiation.
- D. confidentiality and nonrepudiation.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The process of applying a mathematical algorithm to the data that travel in the network and placing the results of this operation with the hash data is used for controlling data integrity, since any unauthorized modification to this data would result in a different hash. The application of a digital signature would accomplish the non- repudiation of the delivery of the message. The term security is a broad concept and not a specific one. In addition to a hash and a digital signature, confidentiality is applied when an encryption process exists.

QUESTION 662

Which of the following would an IS auditor consider a weakness when performing an audit of an organization that uses a public key infrastructure with digital certificates for its business-to- consumer transactions via the internet?

- A. Customers are widely dispersed geographically, but the certificate authorities are not.
- B. Customers can make their transactions from any computer or mobile device.
- C. The certificate authority has several data processing subcenters to administer certificates.
- D. The organization is the owner of the certificate authority.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: If the certificate authority belongs to the same organization, this would generate a conflict of interest. That is, if a customer wanted to repudiate a transaction, they could allege that because of the shared interests, an unlawful agreement exists between the parties generating the certificates, if a customer wanted to repudiate a transaction, they could argue that there exists a bribery between the parties to generate the certificates, as shared interests exist. The other options are not weaknesses.

QUESTION 663

Which of the following implementation modes would provide the GREATEST amount of security for outbound data connecting to the internet?

- A. Transport mode with authentication header (AH) plus encapsulating security payload (ESP)
- B. Secure Sockets Layer (SSL) mode
- C. Tunnel mode with AH plus ESP
- D. Triple-DES encryption mode

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Tunnel mode provides protection to the entire IP package. To accomplish this, AH and ESP services can be nested. The transport mode provides primary protection for the higher layers of the protocols by extending protection to the data fields (payload) of an IP package. The SSL mode provides security to the higher communication layers (transport layer). The triple-DES encryption mode is an algorithm that provides confidentiality.

QUESTION 664

Which of the following is the MOST reliable sender authentication method?

- A. Digital signatures
- B. Asymmetric cryptography
- C. Digital certificates
- D. Message authentication code

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Digital certificates are issued by a trusted third party. The message sender attaches the certificate and the recipient can verify authenticity with the certificate repository. Asymmetric cryptography, such as public key infrastructure (PKI), appears to authenticate the sender but is vulnerable to a man-in-the-middle attack. Digital signatures are used for both authentication and confidentiality, but the identity of the sender would still be confirmed by the digital certificate. Message authentication code is used for message integrity verification.

QUESTION 665

Which of the following provides the GREATEST assurance of message authenticity?

- A. The prehash code is derived mathematically from the message being sent.
- B. The prehash code is encrypted using the sender's private key.
- C. The prehash code and the message are encrypted using the secret key.
- D. The sender attains the recipient's public key and verifies the authenticity of its digital certificate with a certificate authority.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: Encrypting the prehash code using the sender's private key provides assurance of the authenticity of the message. Mathematically deriving the prehash code provides integrity to the message. Encrypting the prehash code and the message using the secretkey provides confidentiality.

QUESTION 666

Which of the following internet security threats could compromise integrity?

- A. Theft of data from the client
- B. Exposure of network configuration information
- C. A Trojan horse browser
- D. Eavesdropping on the net

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Internet security threats/vulnerabilities to integrity include a Trojan horse, which could modify user data, memory and messages found in client-browser software. The other options compromise confidentiality.

QUESTION 667

Which of the following is a concern when data are transmitted through Secure Sockets Layer (SSL) encryption, implemented on a trading partner's server?

- A. The organization does not have control over encryption.
- B. Messages are subjected to wiretapping.
- C. Data might not reach the intended recipient.
- D. The communication may not be secure.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The SSL security protocol provides data encryption, server authentication, message integrity and optional client authentication. Because SSL is built into all major browsers and web servers, simply installing a digital certificate turns on the SSL capabilities. SSL encrypts the datum while it is being transmitted over the internet. The encryption is done in the background, without any interaction from the user; consequently, there is no password to remember. The other choices are incorrect. Since the communication between client and server is encrypted, the confidentiality of information is not affected by wiretapping. Since SSL does the client authentication, only the intended recipient will receive the decrypted data. All data sent over an encrypted SSL connection are protected with a mechanism to detect tampering, i.e., automatically determining whether data has been altered in transit.

QUESTION 668

If inadequate, which of the following would be the MOST likely contributor to a denial-of- service attack?

- A. Router configuration and rules
- B. Design of the internal network
- C. Updates to the router system software
- D. Audit testing and review techniques

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Inadequate router configuration and rules would lead to an exposure to denial-of-service attacks. Choices B and C would be lesser contributors. Choice D is incorrect because audit testing and review techniques are applied after the fact.

QUESTION 669

The Secure Sockets Layer (SSL) protocol addresses the confidentiality of a message through:

- A. symmetric encryption.
- B. message authentication code.
- C. hash function.
- D. digital signature certificates.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

SSL uses a symmetric key for message encryption. A message authentication code is used for ensuring data integrity. Hash function is used for generating a message digest; it does not use public key encryption for message encryption. Digital signature certificates are used by SSL for server authentication.

QUESTION 670

The PRIMARY goal of a web site certificate is:

- A. authentication of the web site that will be surfed.
- B. authentication of the user who surfs through that site.
- C. preventing surfing of the web site by hackers.
- D. the same purpose as that of a digital certificate.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Authenticating the site to be surfed is the primary goal of a web certificate. Authentication of a user is achieved through passwords and not by a web site certificate. The site certificate does not prevent hacking nor does it authenticate a person.

QUESTION 671

An IS auditor performing detailed network assessments and access control reviews should FIRST:

- A. determine the points of entry.
- B. evaluate users' access authorization.
- C. assess users' identification and authorization.
- D. evaluate the domain-controlling server configuration.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

In performing detailed network assessments and access control reviews, an IS auditor should first determine the points of entry to the system and review the points of entry accordingly for appropriate controls. Evaluation of user access authorization, assessment of user identification and authorization, and evaluation of the domain-controlling server configuration are all implementation issues for appropriate controls for the points of entry.

QUESTION 672

The difference between a vulnerability assessment and a penetration test is that a vulnerability assessment:

- A. searches and checks the infrastructure to detect vulnerabilities, whereas penetration testing intends to exploit the vulnerabilities to probe the damage that could result from the vulnerabilities.
- B. and penetration tests are different names for the same activity.
- C. is executed by automated tools, whereas penetration testing is a totally manual process.
- D. is executed by commercial tools, whereas penetration testing is executed by public processes.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The objective of a vulnerability assessment is to find the security holds in the computers and elements analyzed; its intent is not to damage the infrastructure. The intent of penetration testing is to imitate a hacker's activities and determine how far they could go into the network. They are not the same; they have different approaches. Vulnerability assessments and penetration testing can be executed by automated or manual tools or processes and can be executed by commercial or free tools.

QUESTION 673

The most common problem in the operation of an intrusion detection system (IDS) is:

- A. the detection of false positives.
- B. receiving trap messages.
- C. reject-error rates.
- D. denial-of-service attacks.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Because of the configuration and the way IDS technology operates, the main problem in operating IDSs is the recognition (detection) of events that are not really security incidents- false positives, the equivalent of a false

alarm. An IS auditor needs to be aware of this and should check for implementation of related controls, such as IDS tuning, and incident handling procedures, such as the screening process to know if an event is a security incident or a false positive. Trap messages are generated by the Simple Network Management Protocol (SNMP) agents when an important event happens, but are not particularly related to security or IDSs. Reject-error rate is related to biometric technology and is not related to IDSs. Denial-of-service is a type of attack and is not a problem in the operation of IDSs.

QUESTION 674

Which of the following provides nonrepudiation services for e-commerce transactions?

- A. Public key infrastructure (PKI)
- B. Data Encryption Standard (DES)
- C. Message authentication code (MAC)
- D. Personal identification number (PIN)

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: PKI is the administrative infrastructure for digital certificates and encryption key pairs. The qualities of an acceptable digital signature are: it is unique to the person using it; it is capable of verification; it is under the sole control of the person using it; and it is linked to data in such a manner that if data are changed, the digital signature is invalidated. PKI meets these tests. The Data Encryption Standard (DES) is the most common private key cryptographic system. DES does not address nonrepudiation. A MAC is a cryptographic value calculated by passing an entire message through a cipher system. The sender attaches the MAC before transmission and the receiver recalculates the MAC and compares it to the sent MAC. If the two MACs are not equal, this indicates that the message has been altered during transmission; it has nothing to do with nonrepudiation. A PIN is a type of password, a secret number assigned to an individual that, in conjunction with some other means of identification, serves to verify the authenticity of the individual.

QUESTION 675

While copying files from a floppy disk, a user introduced a virus into the network. Which of the following would MOST effectively detect the existence of the virus?

- A. A scan of all floppy disks before use
- B. A virus monitor on the network file server
- C. Scheduled daily scans of all network drives
- D. A virus monitor on the user's personal computer

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Scheduled daily scans of all network drives will detect the presence of a virus after the infection has occurred. All of the other choices are controls designed to prevent a computer virus from infecting the system.

QUESTION 676

Which of the following message services provides the strongest evidence that a specific action has occurred?

- A. Proof of delivery
- B. Nonrepudiation
- C. Proof of submission
- D. Message origin authentication

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Nonrepudiation services provide evidence that a specific action occurred. Nonrepudiation services are similar to their weaker proof counterparts, i.e., proof of submission, proof of delivery and message origin authentication. However, nonrepudiation provides stronger evidence because the proof can be demonstrated to a third party. Digital signatures are used to provide nonrepudiation. Message origination authentication will only confirm the source of the message and does not confirm the specification that has been completed.

QUESTION 677

The PRIMARY objective of Secure Sockets Layer (SSL) is to ensure:

- A. only the sender and receiver are able to encrypt/decrypt the data.
- B. the sender and receiver can authenticate their respective identities.
- C. the alteration of transmitted data can be detected.
- D. the ability to identify the sender by generating a one-time session key.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

SSL generates a session key used to encrypt/decrypt the transmitted data, thus ensuring its confidentiality. Although SSL allows the exchange of X509 certificates to provide for identification and authentication, this feature along with choices C and D are not the primary objectives.

QUESTION 678

The role of the certificate authority (CA) as a third party is to:

- A. provide secured communication and networking services based on certificates.
- B. host a repository of certificates with the corresponding public and secret keys issued by that CA.
- C. act as a trusted intermediary between two communication partners.
- D. confirm the identity of the entity owning a certificate issued by that CA.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The primary activity of a CA is to issue certificates. The primary role of the CA is to check the identity of the entity owning a certificate and to confirm the integrity of any certificate it issued. Providing a communication infrastructure is not a CA activity. The secret keys belonging to the certificates would not be archived at the CA. The CA can contribute to authenticating the communicating partners to each other, but the CA is not involved in the communication stream itself.

QUESTION 679

Which of the following is a distinctive feature of the Secure Electronic Transactions (SET) protocol when used for electronic credit card payments?

- A. The buyer is assured that neither the merchant nor any other party can misuse their credit card data.
- B. All personal SET certificates are stored securely in the buyer's computer.
- C. The buyer is liable for any transaction involving his/her personal SET certificates.
- D. The payment process is simplified, as the buyer is not required to enter a credit card number and an expiration date.

Correct Answer: C

Explanation

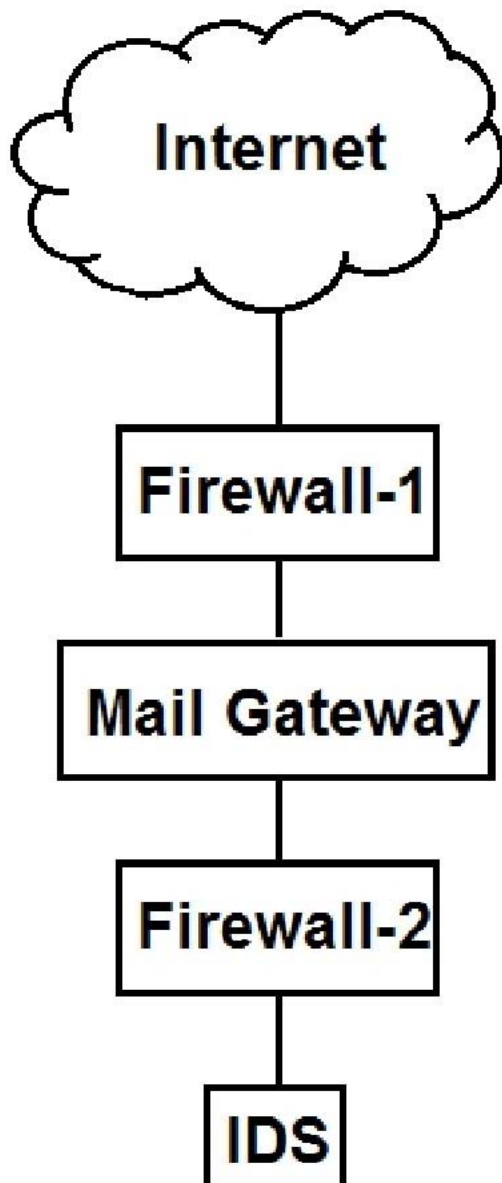
Explanation/Reference:

Section: Protection of Information Assets

The usual agreement between the credit card issuer and the cardholder stipulates that the cardholder assumes responsibility for any use of their personal SET certificates for e-commerce transactions. Depending upon the agreement between the merchant and the buyer's credit card issuer, the merchant will have access to the credit card number and expiration date. Secure data storage in the buyer's computer (local computer security) is not part of the SET standard. Although the buyer is not required to enter their credit card data, they will have to handle the wallet software.

QUESTION 680

E-mail traffic from the Internet is routed via firewall-1 to the mail gateway. Mail is routed from the mail gateway, via firewall-2, to the mail recipients in the internal network. Other traffic is not allowed. For example, the firewalls do not allow direct traffic from the Internet to the internal network.



The intrusion detection system (IDS) detects traffic for the internal network that did not originate from the mail gateway. The FIRST action triggered by the IDS should be to:

- A. alert the appropriate staff.
- B. create an entry in the log.
- C. close firewall-2.
- D. close firewall-1.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Traffic for the internal network that did not originate from the mail gateway is a sign that firewall-1 is not functioning properly. This may have been caused by an attack from a hacker. Closing firewall-2 is the first thing that should be done, thus preventing damage to the internal network. After closing firewall-2, the malfunctioning of firewall-1 can be investigated. The IDS should trigger the closing of firewall-2 either automatically or by manual intervention. Between the detection by the IDS and a response from the system administrator valuable time can be lost, in which a hacker could also compromise firewall-2. An entry in the log is valuable for later analysis, but before that, the IDS should close firewall-2. If firewall-1 has already been compromised by a hacker, it might not be possible for the IDS to close it.

QUESTION 681

An IS auditor should be MOST concerned with what aspect of an authorized honeypot?

- A. The data collected on attack methods
- B. The information offered to outsiders on the honeypot
- C. The risk that the honeypot could be used to launch further attacks on the organization's infrastructure
- D. The risk that the honeypot would be subject to a distributed denial-of-service attack

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Choice C represents the organizational risk that the honeypot could be used as a point of access to launch further attacks on the enterprise's systems. Choices A and B are purposes for deploying a honeypot, not a concern. Choice D, the risk that the honeypot would be subject to a distributed denial-of-service (DDoS) attack, is not relevant, as the honeypot is not a critical device for providing service.

QUESTION 682

Which of the following should be a concern to an IS auditor reviewing a wireless network?

- A. 128-bit static-key WEP (Wired Equivalent Privacy) encryption is enabled.
- B. SSID (Service Set Identifier) broadcasting has been enabled.
- C. Antivirus software has been installed in all wireless clients.
- D. MAC (Media Access Control) access control filtering has been deployed.

Correct Answer: B

Explanation

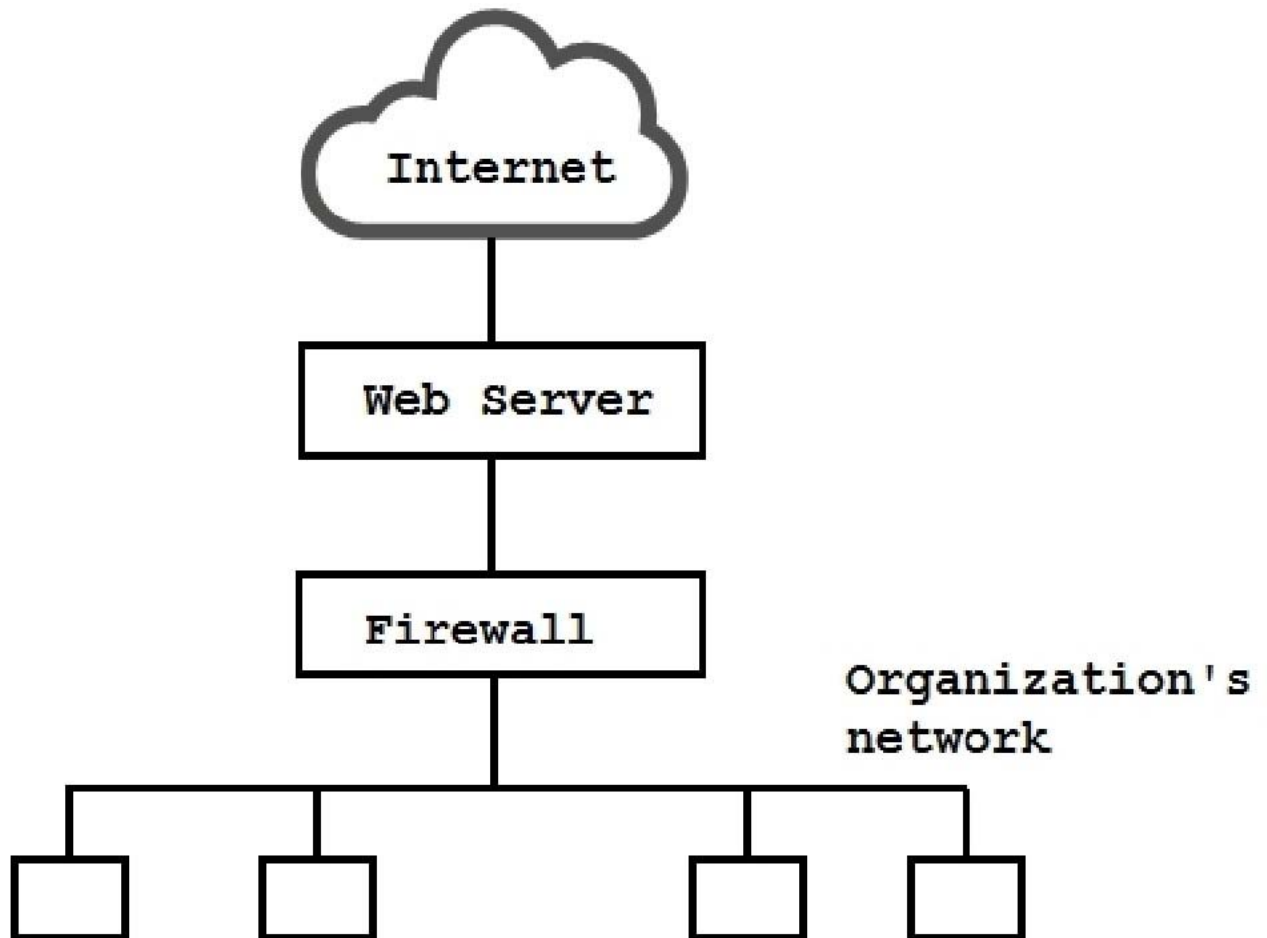
Explanation/Reference:

Section: Protection of Information Assets

SSID broadcasting allows a user to browse for available wireless networks and to access them without authorization. Choices A, C and D are used to strengthen a wireless network.

QUESTION 683

To detect attack attempts that the firewall is unable to recognize, an IS auditor should recommend placing a network intrusion detection system (IDS) between the:



- A. Firewall and the organization's network.
- B. Internet and the firewall.
- C. Internet and the web server.
- D. Web server and the firewall.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Attack attempts that could not be recognized by the firewall will be detected if a network-based intrusion detection system is placed between the firewall and the organization's network. A network-based intrusion detection system placed between the internet and the firewall will detect attack attempts, whether they do or do not enter the firewall.

QUESTION 684

Which of the following ensures a sender's authenticity and an e-mail's confidentiality?

- A. Encrypting the hash of the message with the sender's private key and thereafter encrypting the hash of the message with the receiver's public key
- B. The sender digitally signing the message and thereafter encrypting the hash of the message with the sender's private key
- C. Encrypting the hash of the message with the sender's private key and thereafter encrypting the message with the receiver's public key
- D. Encrypting the message with the sender's private key and encrypting the message hash with the receiver's public key.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

To ensure authenticity and confidentiality, a message must be encrypted twice: first with the sender's private key, and then with the receiver's public key. The receiver can decrypt the message, thus ensuring confidentiality of the message. Thereafter, the decrypted message can be decrypted with the public key of the sender, ensuring authenticity of the message. Encrypting the message with the sender's private key enables anyone to decrypt it.

QUESTION 685

An efficient use of public key infrastructure (PKI) should encrypt the:

- A. entire message.
- B. private key.
- C. public key.
- D. symmetric session key.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Public key (asymmetric) cryptographic systems require larger keys (1,024 bits) and involve intensive and time-consuming computations. In comparison, symmetric encryption is considerably faster, yet relies on the security of the process for exchanging the secret key. To enjoy the benefits of both systems, a symmetric session key is exchanged using public key methods, after which it serves as the secret key for encrypting/decrypting messages sent between two parties.

QUESTION 686

Which of the following cryptographic systems is MOST appropriate for bulk data encryption and small devices such as smart cards?

- A. DES
- B. AES
- C. Triple DES
- D. RSA

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Advanced Encryption Standard (AES), a public algorithm that supports keys from 128 to 256 bits in size, not only provides good security, but provides speed and versatility across a variety of computer platforms. AES runs securely and efficiently on large computers, desktop computers and even small devices such as smart cards. DES is not considered a strong cryptographic solution since its entire key space can be brute forced by large computer systems within a relatively short period of time. Triple DES can take up to three times longer than DES to perform encryption and decryption. RSA keys are large numbers that are suitable only for short messages, such as the creation of a digital signature.

QUESTION 687

Disabling which of the following would make wireless local area networks more secure against unauthorized access?

- A. MAC (Media Access Control) address filtering
- B. WPA (Wi-Fi Protected Access Protocol)
- C. LEAP (Lightweight Extensible Authentication Protocol)
- D. SSID (service set identifier) broadcasting

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Disabling SSID broadcasting adds security by making it more difficult for unauthorized users to find the name of the access point. Disabling MAC address filtering would reduce security. Using MAC filtering makes it more difficult to access a WLAN, because it would be necessary to catch traffic and forge the MAC address. Disabling WPA reduces security. Using WPA adds security by encrypting the traffic. Disabling LEAP reduces security. Using LEAP adds security by encrypting the wireless traffic.

QUESTION 688

Which of the following is BEST suited for secure communications within a small group?

- A. Key distribution center
- B. Certification authority
- C. Web of trust
- D. Kerberos Authentication System

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Web of trust is a key distribution method suitable for communication in a small group. It ensures pretty good privacy (PGP) and distributes the public keys of users within a group. Key distribution center is a distribution method suitable for internal communication for a large group within an institution, and it will distribute symmetric keys for each session. Certification authority is a trusted third party that ensures the authenticity of the owner of the certificate. This is necessary for large groups and formal communication. A Kerberos

Authentication System extends the function of a key distribution center, by generating 'tickets' to define the facilities on networked machines which are accessible to each user.

QUESTION 689

Which of the following is the MOST important action in recovering from a cyberattack?

- A. Creation of an incident response team
- B. Use of cyber forensic investigators
- C. Execution of a business continuity plan
- D. Filing an insurance claim

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: The most important key step in recovering from cyberattacks is the execution of a business continuity plan to quickly and cost-effectively recover critical systems, processes and data. The incident response team should exist prior to a cyberattack. When a cyberattack is suspected, cyber forensic investigators should be used to set up alarms, catch intruders within the network, and track and trace them over the Internet. After taking the above steps, an organization may have a residual risk that needs to be insured and claimed for traditional and electronic exposures.

QUESTION 690

What method might an IS auditor utilize to test wireless security at branch office locations?

- A. War dialing
- B. Social engineering

- C. War driving
- D. Password cracking

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

War driving is a technique for locating and gaining access to wireless networks by driving or walking with a wireless equipped computer around a building. War dialing is a technique for gaining access to a computer or a network through the dialing of defined blocks of telephone numbers, with the hope of getting an answer from a modem. Social engineering is a technique used to gather information that can assist an attacker in gaining logical or physical access to data or resources. Social engineering exploits human weaknesses. Password crackers are tools used to guess users' passwords by trying combinations and dictionary words.

QUESTION 691

In a public key infrastructure, a registration authority:

- A. verifies information supplied by the subject requesting a certificate.
- B. issues the certificate after the required attributes are verified and the keys are generated.
- C. digitally signs a message to achieve nonrepudiation of the signed message.
- D. registers signed messages to protect them from future repudiation.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A registration authority is responsible for verifying information supplied by the subject requesting a certificate, and verifies the requestor's right to request certificate attributes and that the requestor actually possesses the private key corresponding to the public key being sent.

Certification authorities, not registration authorities, actually issue certificates once verification of the information has been completed; because of this, choice B is incorrect. On the other hand, the sender who has control of their private key signs the message, not the registration authority. Registering signed messages is not a task performed by registration authorities.

QUESTION 692

Confidentiality of the data transmitted in a wireless LAN is BEST protected if the session is:

- A. restricted to predefined MAC addresses.
- B. encrypted using static keys.
- C. encrypted using dynamic keys.
- D. initiated from devices that have encrypted storage.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

When using dynamic keys, the encryption key is changed frequently, thus reducing the risk of the key being compromised and the message being decrypted.

Limiting the number of devices that can access the network does not address the issue of encrypting the session. Encryption with static keys-using the same key for a long period of time-risks that the key would be compromised. Encryption of the data on the connected device (laptop, PDA, etc.) addresses the confidentiality of the data on the device, not the wireless session.

QUESTION 693

Which of the following provides the MOST relevant information for proactively strengthening security settings?

- A. Bastion host
- B. Intrusion detection system
- C. Honeypot
- D. Intrusion prevention system

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The design of a honeypot is such that it lures the hacker and provides clues as to the hacker's methods and strategies and the resources required to address such attacks. A bastion host does not provide information about an attack. Intrusion detection systems and intrusion prevention systems are designed to detect and address an attack in progress and stop it as soon as possible. A honeypot allows the attack to continue, so as to obtain information about the hacker's strategy and methods.

QUESTION 694

Over the long term, which of the following has the greatest potential to improve the security incident response process?

- A. A walkthrough review of incident response procedures
- B. Postevent reviews by the incident response team
- C. Ongoing security training for users
- D. Documenting responses to an incident

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Postevent reviews to find the gaps and shortcomings in the actual incident response processes will help to improve the process over time. Choices A, C and D are desirable actions, but postevent reviews are the most reliable mechanism for improving security incident response processes.

QUESTION 695

When reviewing an intrusion detection system (IDS), an IS auditor should be MOST concerned about which of the following?

- A. Number of nonthreatening events identified as threatening
- B. Attacks not being identified by the system

- C. Reports/logs being produced by an automated tool
- D. Legitimate traffic being blocked by the system

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Attacks not being identified by the system present a higher risk, because they are unknown and no action will be taken to address the attack. Although the number of false-positives is a serious issue, the problem will be known and can be corrected. Often, IDS reports are first analyzed by an automated tool to eliminate known false-positives, which generally are not a problem. An IDS does not block any traffic.

QUESTION 696

Distributed denial-of-service (DDOS) attacks on Internet sites are typically evoked by hackers using which of the following?

- A. Logic bombs
- B. Phishing
- C. Spyware
- D. Trojan horses

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Trojan horses are malicious or damaging code hidden within an authorized computer program. Hackers use Trojans to mastermind DDOS attacks that affect computers that access the same Internet site at the same moment, resulting in overloaded site servers that may no longer be able to process legitimate requests. Logic bombs are programs designed to destroy or modify data at a specific time in the future. Phishing is an attack, normally via e-mail, pretending to be an authorized person or organization requesting information. Spyware is a program that picks up information from PC drives by making copies of their contents.

QUESTION 697

Validated digital signatures in an e-mail software application will:

- A. help detect spam.
- B. provide confidentiality.
- C. add to the workload of gateway servers.
- D. significantly reduce available bandwidth.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Validated electronic signatures are based on qualified certificates that are created by a certification authority (CA), with the technical standards required to ensure the key can neither be forced nor reproduced in a reasonable time. Such certificates are only delivered through a registration authority (RA) after a proof of identity has been passed. Using strong signatures in e-mail traffic, nonrepudiation can be assured and a sender can be tracked. The recipient can configure their e-mail server or client to automatically delete e-mails from specific senders. For confidentiality issues, one must use encryption, not a signature, although both methods can be based on qualified certificates. Without any filters directly applied on mail gateway servers to block traffic without strong signatures, the workload will not increase. Using filters directly on a gateway server will result in an overhead less than antivirus software imposes. Digital signatures are only a few bytes in size and will not slash bandwidth. Even if gateway servers were to check CRLs, there is little overhead.

QUESTION 698

In transport mode, the use of the Encapsulating Security Payload (ESP) protocol is advantageous over the Authentication Header (AH) protocol because it provides:

- A. connectionless integrity.
- B. data origin authentication.
- C. antireplay service.
- D. confidentiality.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Both protocols support choices A, B and C, but only the ESP protocol provides confidentiality via encryption.

QUESTION 699

An IS auditor notes that IDS log entries related to port scanning are not being analyzed. This lack of analysis will MOST likely increase the risk of success of which of the following attacks?

- A. Denial-of-service
- B. Replay
- C. Social engineering
- D. Buffer overflow

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Prior to launching a denial-of-service attack, hackers often use automatic port scanning software to acquire

information about the subject of their attack. A replay attack is simply sending the same packet again. Social engineering exploits end-user vulnerabilities, and buffer overflow attacks exploit poorly written code.

QUESTION 700

IS management recently replaced its existing wired local area network (LAN) with a wireless infrastructure to accommodate the increased use of mobile devices within the organization. This will increase the risk of which of the following attacks?

- A. Port scanning
- B. Back door
- C. Man-in-the-middle
- D. War driving

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A war driving attack uses a wireless Ethernet card, set in promiscuous mode, and a powerful antenna to penetrate wireless systems from outside. Port scanning will often target the external firewall of the organization. A back door is an opening left in software that enables an unknown entry into a system. Man-in-the-middle attacks intercept a message and either replace or modify it.

QUESTION 701

Which of the following encryption techniques will BEST protect a wireless network from a man-in-the-middle attack?

- A. 128-bit wired equivalent privacy (WEP)
- B. MAC-based pre-shared key (PSK)
- C. Randomly generated pre-shared key (PSK)
- D. Alphanumeric service set identifier (SSID)

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A randomly generated PSK is stronger than a MAC-based PSK, because the MAC address of a computer is fixed and often accessible. WEP has been shown to be a very weak encryption technique and can be cracked within minutes. The SSID is broadcast on the wireless network in plaintext.

QUESTION 702

The IS management of a multinational company is considering upgrading its existing virtual private network (VPN) to support voice-over IP (VoIP) communications via tunneling. Which of the following considerations should be PRIMARILY addressed?

- A. Reliability and quality of service (QoS)
- B. Means of authentication
- C. Privacy of voice transmissions
- D. Confidentiality of data transmissions

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The company currently has a VPN; issues such as authentication and confidentiality have been implemented by the VPN using tunneling. Privacy of voice transmissions is provided by the VPN protocol. Reliability and QoS are, therefore, the primary considerations to be addressed.

QUESTION 703

Which of the following antispam filtering techniques would BEST prevent a valid, variable-length e-mail message containing a heavily weighted spam keyword from being labeled as spam?

- A. Heuristic (rule-based)
- B. Signature-based
- C. Pattern matching
- D. Bayesian (statistical)

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Bayesian filtering applies statistical modeling to messages, by performing a frequency analysis on each word within the message and then evaluating the message as a whole. Therefore, it can ignore a suspicious keyword if the entire message is within normal bounds. Heuristic filtering is less effective, since new exception rules may need to be defined when a valid message is labeled as spam. Signature-based filtering is useless against variable-length messages, because the calculated MD5 hash changes all the time. Finally, pattern matching is actually a degraded rule-based technique, where the rules operate at the word level using wildcards, and not at higher levels.

QUESTION 704

Which of the following public key infrastructure (PKI) elements provides detailed descriptions for dealing with a compromised private key?

- A. Certificate revocation list (CRL)
- B. Certification practice statement (CPS)
- C. Certificate policy (CP)
- D. PKI disclosure statement (PDS)

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The CPS is the how-to part in policy-based PKI. The CRL is a list of certificates that have been revoked before their scheduled expiration date. The CP sets the requirements that are subsequently implemented by the CPS. The PDS covers critical items such as the warranties, limitations and obligations that legally bind each party.

QUESTION 705

Active radio frequency ID (RFID) tags are subject to which of the following exposures?

- A. Session hijacking

- B. Eavesdropping
- C. Malicious code
- D. Phishing

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Like wireless devices, active RFID tags are subject to eavesdropping. They are by nature not subject to session hijacking, malicious code or phishing.

QUESTION 706

When conducting a penetration test of an organization's internal network, which of the following approaches would BEST enable the conductor of the test to remain undetected on the network?

- A. Use the IP address of an existing file server or domain controller.
- B. Pause the scanning every few minutes to allow thresholds to reset.
- C. Conduct the scans during evening hours when no one is logged-in.
- D. Use multiple scanning tools since each tool has different characteristics.

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Pausing the scanning every few minutes avoids overtaxing the network as well as exceeding thresholds that may trigger alert messages to the network administrator. Using the IP address of a server would result in an address contention that would attract attention. Conducting scans after hours would increase the chance of detection, since there would be less traffic to conceal ones activities. Using different tools could increase the likelihood that one of them would be detected by an intrusion detection system.

QUESTION 707

Two-factor authentication can be circumvented through which of the following attacks?

- A. Denial-of-service
- B. Man-in-the-middle
- C. Key logging
- D. Brute force

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

A man-in-the-middle attack is similar to piggybacking, in that the attacker pretends to be the legitimate destination, and then merely retransmits whatever is sent by the authorized user along with additional transactions after authentication has been accepted. A denial-of- service attack does not have a relationship to authentication. Key logging and brute force could circumvent a normal authentication but not a two-factor authentication.

QUESTION 708

An organization can ensure that the recipients of e-mails from its employees can authenticate the identity of the sender by:

- A. digitally signing all e-mail messages.
- B. encrypting all e-mail messages.
- C. compressing all e-mail messages.
- D. password protecting all e-mail messages.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

By digitally signing all e-mail messages, the receiver will be able to validate the authenticity of the sender. Encrypting all e-mail messages would ensure that only the intended recipient will be able to open the message; however, it would not ensure the authenticity of the sender. Compressing all e-mail messages would reduce the size of the message, but would not ensure the authenticity. Password protecting all e-mail messages would ensure that only those who have the password would be able to open the message; however, it would not ensure the authenticity of the sender.

QUESTION 709

Sending a message and a message hash encrypted by the sender's private key will ensure:

- A. authenticity and integrity.
- B. authenticity and privacy.
- C. integrity and privacy.
- D. privacy and nonrepudiation.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

If the sender sends both a message and a message hash encrypted by its private key, then the receiver can apply the sender's public key to the hash and get the message hash. The receiver can apply the hashing algorithm to the message received and generate a hash. By matching the generated hash with the one received, the receiver is ensured that the message has been sent by the specific sender, i.e., authenticity, and that the message has not been changed enroute. Authenticity and privacy will be ensured by first using the sender's private key and then the receiver's public key to encrypt the message. Privacy and integrity can be ensured by using the receiver's public key to encrypt the message and sending a message hash/digest. Only nonrepudiation can be ensured by using the sender's private key to encrypt the message. The sender's public key, available to anyone, can decrypt a message; thus, it does not ensure privacy.

QUESTION 710

Which of the following is a passive attack to a network?

- A. Message modification

- B. Masquerading
- C. Denial of service
- D. Traffic analysis

Correct Answer: D
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The intruder determines the nature of the flow of traffic (traffic analysis) between defined hosts and is able to guess the type of communication taking place. Message modification involves the capturing of a message and making unauthorized changes or deletions, changing the sequence or delaying transmission of captured messages. Masquerading is an active attack in which the intruder presents an identity other than the original identity. Denial of service occurs when a computer connected to the internet is flooded with data and/or requests that must be processed.

QUESTION 711

An organization has a mix of access points that cannot be upgraded to stronger security and newer access points having advanced wireless security. An IS auditor recommends replacing the non-upgradeable access points. Which of the following would BEST justify the IS auditor's recommendation?

- A. The new access points with stronger security are affordable.
- B. The old access points are poorer in terms of performance.
- C. The organization's security would be as strong as its weakest points.
- D. The new access points are easier to manage.

Correct Answer: C
Explanation

Explanation/Reference:

Section: Protection of Information Assets

The old access points should be discarded and replaced with products having strong security; otherwise, they will leave security holes open for attackers and thus make the entire network as weak as they are. Affordability is not the auditor's major concern. Performance is not as important as security in this situation. Product manageability is not the IS auditor's concern.

QUESTION 712

An investment advisor e-mails periodic newsletters to clients and wants reasonable assurance that no one has modified the newsletter. This objective can be achieved by:

- A. encrypting the hash of the newsletter using the advisor's private key.
- B. encrypting the hash of the newsletter using the advisor's public key.
- C. digitally signing the document using the advisor's private key.
- D. encrypting the newsletter using the advisor's private key.

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

There is no attempt on the part of the investment advisor to prove their identity or to keep the newsletter confidential. The objective is to assure the receivers that it came to them without any modification, i.e., it has message integrity. Choice A is correct because the hash is encrypted using the advisor's private key. The recipients can open the newsletter, recompute the hash and decrypt the received hash using the advisor's public key. If the two hashes are equal, the newsletter was not modified in transit. Choice B is not feasible, for no one other than the investment advisor can open it. Choice C addresses sender authentication but not message integrity. Choice D addresses confidentiality, but not message integrity, because anyone can obtain the investment advisor's public key, decrypt the newsletter, modify it and send it to others. The interceptor will not be able to use the advisor's private key, because they do not have it. Anything encrypted using the interceptor's private key can be decrypted by the receiver only by using their public key.

QUESTION 713

An IS auditor reviewing wireless network security determines that the Dynamic Host Configuration Protocol is disabled at all wireless access points. This practice:

- A. reduces the risk of unauthorized access to the network.
- B. is not suitable for small networks.
- C. automatically provides an IP address to anyone.
- D. increases the risks associated with Wireless Encryption Protocol (WEP).

Correct Answer: A
Explanation

Explanation/Reference:

Section: Protection of Information Assets

Dynamic Host Configuration Protocol (DHCP) automatically assigns IP addresses to anyone connected to the network. With DHCP disabled, static IP addresses must be used and represent less risk due to the potential for address contention between an unauthorized device and existing devices on the network. Choice B is incorrect because DHCP is suitable for small networks. Choice C is incorrect because DHCP does not provide IP addresses when disabled. Choice D is incorrect because disabling of the DHCP makes it more difficult to exploit the well-known weaknesses in WEP.

QUESTION 714

A virtual private network (VPN) provides data confidentiality by using:

- A. Secure Sockets Layer (SSL)
- B. Tunneling
- C. Digital signatures
- D. Phishing

Correct Answer: B
Explanation

Explanation/Reference:

Section: Protection of Information Assets

VPNs secure data in transit by encapsulating traffic, a process known as tunneling. SSL is a symmetric method of encryption between a server and a browser.

Digital signatures are not used in the VPN process, while phishing is a form of a social engineering attack.

QUESTION 715

In auditing a web server, an IS auditor should be concerned about the risk of individuals gaining unauthorized access to confidential information through:

- A. common gateway interface (CGI) scripts.
- B. enterprise Java beans (EJBs).
- C. applets.
- D. web services.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Explanation: Common gateway interface (CGI) scripts are executable machine independent software programs on the server that can be called and executed by a web server page. CGI performs specific tasks such as processing inputs received from clients. The use of CGI scripts needs to be evaluated, because as they run in the server, a bug in them may allow a user to gain unauthorized access to the server and from

there gain access to the organization's network.

Applets are programs downloaded from a web server and executed on web browsers on client machines to run any web-based applications. Enterprise java beans (EJBs) and web services have to be deployed by the web server administrator and are controlled by the application server. Their execution requires knowledge of the parameters and expected return values.

QUESTION 716

An IS auditor reviewing access controls for a client-server environment should FIRST:

- A. evaluate the encryption technique.
- B. identify the network access points.
- C. review the identity management system.
- D. review the application level access controls.

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A client-server environment typically contains several access points and utilizes distributed techniques, increasing the risk of unauthorized access to data and processing. To evaluate the security of the client server environment, all network access points should be identified. Evaluating encryption techniques, reviewing the identity management system and reviewing the application level access controls would be performed at a later stage of the review.

QUESTION 717

To prevent IP spoofing attacks, a firewall should be configured to drop a packet if:

- A. the source routing field is enabled.
- B. it has a broadcast address in the destination field.
- C. a reset flag (RST) is turned on for the TCP connection.
- D. dynamic routing is used instead of static routing.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

IP spoofing takes advantage of the source-routing option in the IP protocol. With this option enabled, an attacker can insert a spoofed source IP address. The packet will travel the network according to the information within the source-routing field, bypassing the logic in each router, including dynamic and static routing (choice D). Choices B and C do not have any relation to IP spoofing attacks. If a packet has a broadcast destination address (choice B), it will be sent to all addresses in the subnet. Turning on the reset flag (RST) (choice C) is part of the normal procedure to end a TCP connection.

QUESTION 718

An IS auditor reviewing the implementation of an intrusion detection system (IDS) should be MOST concerned if:

- A. IDS sensors are placed outside of the firewall.
- B. a behavior-based IDS is causing many false alarms.
- C. a signature-based IDS is weak against new types of attacks.
- D. the IDS is used to detect encrypted traffic.

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

An intrusion detection system (IDS) cannot detect attacks within encrypted traffic, and it would be a concern if someone was misinformed and thought that the IDS could detect attacks in encrypted traffic. An organization can place sensors outside of the firewall to detect attacks.

These sensors are placed in highly sensitive areas and on extranets. Causing many false alarms is normal for a behavior-based IDS, and should not be a matter of concern. Being weak against new types of attacks is also expected from a signature-based IDS, because it can only recognize attacks that have been previously identified.

QUESTION 719

Which of the following BEST describes the role of a directory server in a public key infrastructure (PKI)?

- A. Encrypts the information transmitted over the network
- B. Makes other users' certificates available to applications
- C. Facilitates the implementation of a password policy
- D. Stores certificate revocation lists (CRLs)

Correct Answer: B

Explanation

Explanation/Reference:

Section: Protection of Information Assets

A directory server makes other users' certificates available to applications. Encrypting the information transmitted over the network and storing certificate revocation lists (CRLs) are roles performed by a security server. Facilitating the implementation of a password policy is not relevant to public key infrastructure (PKI).

QUESTION 720

An organization is using symmetric encryption. Which of the following would be a valid reason for moving to asymmetric encryption? Symmetric encryption:

- A. provides authenticity.
- B. is faster than asymmetric encryption.
- C. can cause key management to be difficult.
- D. requires a relatively simple algorithm.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

In a symmetric algorithm, each pair of users' needs a unique pair of keys, so the number of keys grows and key management can become overwhelming. Symmetric algorithms do not provide authenticity, and symmetric encryption is faster than asymmetric encryption. Symmetric algorithms require mathematical calculations, but they are not as complex as asymmetric algorithms.

QUESTION 721

Which of the following would provide the BEST protection against the hacking of a computer connected to the Internet?

- A. A remote access server
- B. A proxy server
- C. A personal firewall
- D. A password-generating token

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A personal firewall is the best way to protect against hacking, because it can be defined with rules that describe the type of user or connection that is or is not permitted. A remote access server can be mapped or scanned from the Internet, creating security exposures. Proxy servers can provide protection based on the IP address and ports; however, an individual would need to have in-depth knowledge to do this, and applications can use different ports for the different sections of their program. A password-generating token may help to encrypt the session but does not protect a computer against hacking.

QUESTION 722

When installing an intrusion detection system (IDS), which of the following is MOST important?

- A. Properly locating it in the network architecture
- B. Preventing denial-of-service (DoS) attacks
- C. Identifying messages that need to be quarantined
- D. Minimizing the rejection errors

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Proper location of an intrusion detection system (IDS) in the network is the most important decision during installation. A poorly located IDS could leave key areas of the network unprotected. Choices B, C and D are concerns during the configuration of an IDS, but if the IDS is not placed correctly, none of them would be adequately addressed.

QUESTION 723

In a public key infrastructure (PKI), which of the following may be relied upon to prove that an online transaction was authorized by a specific customer?

- A. Nonrepudiation
- B. Encryption
- C. Authentication
- D. Integrity

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Nonrepudiation, achieved through the use of digital signatures, prevents the claimed sender from later denying that they generated and sent the message. Encryption may protect the data transmitted over the Internet, but may not prove that the transactions were made. Authentication is necessary to establish the identification of all parties to a communication. Integrity ensures that transactions are accurate but does not provide the

identification of the customer.

QUESTION 724

Which of the following ensures confidentiality of information sent over the internet?

- A. Digital signature
- B. Digital certificate
- C. Online Certificate Status Protocol
- D. Private key cryptosystem

Correct Answer: D

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Confidentiality is assured by a private key cryptosystem. Digital signatures assure data integrity, authentication and nonrepudiation, but not confidentiality. A digital certificate is a certificate that uses a digital signature to bind together a public key with an identity; therefore, it does not address confidentiality. Online Certificate Status Protocol (OCSP) is an Internet protocol used for obtaining the revocation status of a digital certificate.

QUESTION 725

To protect a VoIP infrastructure against a denial-of-service (DoS) attack, it is MOST important to secure the:

- A. access control servers.
- B. session border controllers.
- C. backbone gateways.
- D. intrusion detection system (IDS).

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Session border controllers enhance the security in the access network and in the core. In the access network, they hide a user's real address and provide a managed public address. This public address can be monitored, minimizing the opportunities for scanning and denial-of-service (DoS) attacks. Session border controllers permit access to clients behind firewalls while maintaining the firewall's effectiveness. In the core, session border controllers protect the users and the network. They hide network topology and users' real addresses. They can also monitor bandwidth and quality of service. Securing the access control server, backbone gateways and intrusion detection systems (IDSs) does not effectively protect against DoS attacks.

QUESTION 726

Which of the following attacks targets the Secure Sockets Layer (SSL)?

- A. Man-in-the middle
- B. Dictionary
- C. Password sniffing
- D. Phishing

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Attackers can establish a fake Secure Sockets Layer (SSL) server to accept user's SSL traffic and then route to the real SSL server, so that sensitive information can be discovered. A dictionary attack that has been launched to discover passwords would not attack SSL since SSL does not rely on passwords. SSL traffic is encrypted; thus it is not possible to sniff the password. A phishing attack targets a user and not SSL. Phishing attacks attempt to have the user surrender private information by falsely claiming to be a trusted person or enterprise.

QUESTION 727

Which of the following potentially blocks hacking attempts?

- A. intrusion detection system
- B. Honeypot system
- C. Intrusion prevention system
- D. Network security scanner

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

An intrusion prevention system (IPS) is deployed as an in-line device that can detect and block hacking attempts. An intrusion detection system (IDS) normally is deployed in sniffing mode and can detect intrusion attempts, but cannot effectively stop them. A honeypot solution traps the intruders to explore a simulated target. A network security scanner scans for the vulnerabilities, but it will not stop the intrusion.

QUESTION 728

A web server is attacked and compromised. Which of the following should be performed FIRST to handle the incident?

- A. Dump the volatile storage data to a disk.
- B. Run the server in a fail-safe mode.
- C. Disconnect the web server from the network.
- D. Shut down the web server.

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The first action is to disconnect the web server from the network to contain the damage and prevent more actions by the attacker. Dumping the volatile storage data to a disk may be used at the investigation stage but does not contain an attack in progress. To run the server in a fail-safe mode, the server needs to be shut down. Shutting down the server could potentially erase information that might be needed for a forensic investigation or to develop a strategy to prevent future similar attacks.

QUESTION 729

To address a maintenance problem, a vendor needs remote access to a critical network. The MOST secure and effective solution is to provide the vendor with a:

- A. Secure Shell (SSH-2) tunnel for the duration of the problem.
- B. two-factor authentication mechanism for network access.
- C. dial-in access.
- D. virtual private network (VPN) account for the duration of the vendor support contract.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

For granting temporary access to the network, a Secure Shell (SSH-2) tunnel is the best approach. It has auditing features and allows restriction to specific access points. Choices B, C and D all give full access to the internal network. Two-factor authentication and virtual private network (VPN) provide access to the entire network and are suitable for dedicated users. Dial-in access would need to be closely monitored or reinforced with another mechanism to ensure authentication to achieve the same level of security as SSH-2.

QUESTION 730

What is the BEST approach to mitigate the risk of a phishing attack?

- A. implement an intrusion detection system (IDS)
- B. Assess web site security
- C. Strong authentication
- D. User education

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Phishing attacks can be mounted in various ways; intrusion detection systems (IDSs) and strong authentication cannot mitigate most types of phishing attacks. Assessing web site security does not mitigate the risk. Phishing uses a server masquerading as a legitimate server. The best way to mitigate the risk of phishing is to educate users to take caution with suspicious internet communications and not to trust them until verified. Users require adequate training to recognize suspicious web pages and e-mail.

QUESTION 731

A sender of an e-mail message applies a digital signature to the digest of the message. This action provides assurance of the:

- A. date and time stamp of the message.
- B. identity of the originating computer.
- C. confidentiality of the message's content.
- D. authenticity of the sender.

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The signature on the digest can be used to authenticate the sender. It does not provide assurance of the date and time stamp or the identity of the originating computer. Digitally signing an e-mail message does not prevent access to its content and, therefore, does not assure confidentiality.

QUESTION 732

The BEST filter rule for protecting a network from being used as an amplifier in a denial of service (DoS) attack is to deny all:

- A. outgoing traffic with IP source addresses external to the network.
- B. incoming traffic with discernible spoofed IP source addresses.
- C. incoming traffic with IP options set.
- D. incoming traffic to critical hosts.

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Outgoing traffic with an IP source address different than the IP range in the network is invalid, in most of the cases, it signals a DoS attack originated by an internal user or by a previously compromised internal machine; in both cases, applying this filter will stop the attack.

QUESTION 733

The network of an organization has been the victim of several intruders' attacks. Which of the following measures would allow for the early detection of such incidents?

- A. Antivirus software
- B. Hardening the servers
- C. Screening routers
- D. Honeypots

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Honeypots can collect data on precursors of attacks. Since they serve no business function, honeypots are hosts that have no authorized users other than the honeypot administrators. All activity directed at them is considered suspicious. Attackers will scan and attack honeypots, giving administrators data on new trends and attack tools, particularly malicious code. However, honeypots are a supplement to, not a replacement for, properly securing networks, systems and applications. If honeypots are to be used by an organization, qualified incident handlers and intrusion detection analysts should manage them. The other choices do not provide indications of potential attacks.

QUESTION 734

A company has decided to implement an electronic signature scheme based on public key infrastructure. The user's private key will be stored on the computer's hard drive and protected by a password. The MOST significant risk of this approach is:

- A. use of the user's electronic signature by another person if the password is compromised.
- B. forgery by using another user's private key to sign a message with an electronic signature.
- C. impersonation of a user by substitution of the user's public key with another person's public key.
- D. forgery by substitution of another person's private key on the computer.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The user's digital signature is only protected by a password. Compromise of the password would enable access to the signature. This is the most significant risk. Choice B would require subversion of the public key

infrastructure mechanism, which is very difficult and least likely. Choice C would require that the message appear to have come from a different person and therefore the true user's credentials would not be forged. Choice D has the same consequence as choice C.

QUESTION 735

An IS auditor selects a server for a penetration test that will be carried out by a technical specialist. Which of the following is MOST important?

- A. The tools used to conduct the test
- B. Certifications held by the IS auditor
- C. Permission from the data owner of the server
- D. An intrusion detection system (IDS) is enabled

Correct Answer: C

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The data owner should be informed of the risks associated with a penetration test, what types of tests are to be conducted and other relevant details. All other choices are not as important as the data owner's responsibility for the security of the data assets.

QUESTION 736

After observing suspicious activities in a server, a manager requests a forensic analysis. Which of the following findings should be of MOST concern to the investigator?

- A. Server is a member of a workgroup and not part of the server domain
- B. Guest account is enabled on the server
- C. Recently, 100 users were created in the server
- D. Audit logs are not enabled for the server

Correct Answer: D

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Audit logs can provide evidence which is required to proceed with an investigation and should not be disabled. For business needs, a server can be a member of a workgroup and, therefore, not a concern. Having a guest account enabled on a system is a poor security practice but not a forensic investigation concern. Recently creating 100 users in the server may have been required to meet business needs and should not be a concern.

QUESTION 737

Which of the following would be the GREATEST cause for concern when data are sent over the Internet using HTTPS protocol?

- A. Presence of spyware in one of the ends
- B. The use of a traffic sniffing tool
- C. The implementation of an RSA-compliant solution
- D. A symmetric cryptography is used for transmitting data

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

Encryption using secure sockets layer/transport layer security (SSL/TLS) tunnels makes it difficult to intercept data in transit, but when spyware is running on an end user's computer, data are collected before encryption takes place. The other choices are related to encrypting the traffic, but the presence of spyware in one of the ends captures the data before encryption takes place.

QUESTION 738

A firewall is being deployed at a new location. Which of the following is the MOST important factor in ensuring a successful deployment?

- A. Reviewing logs frequently
- B. Testing and validating the rules
- C. Training a local administrator at the new location
- D. Sharing firewall administrative duties

Correct Answer: B

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

A mistake in the rule set can render a firewall insecure. Therefore, testing and validating the rules is the most important factor in ensuring a successful deployment. A regular review of log files would not start until the deployment has been completed. Training a local administrator may not be necessary if the firewalls are managed from a central location. Having multiple administrators is a good idea, but not the most important.

QUESTION 739

The human resources (HR) department has developed a system to allow employees to enroll in benefits via a web site on the corporate Intranet. Which of the following would protect the confidentiality of the data?

- A. SSL encryption
- B. Two-factor authentication
- C. Encrypted session cookies
- D. IP address verification

Correct Answer: A

Explanation**Explanation/Reference:**

Section: Protection of Information Assets

The main risk in this scenario is confidentiality, therefore the only option which would provide confidentiality is Secure Socket Layer (SSL) encryption. The remaining options deal with authentication issues.

QUESTION 740

What is the MOST prevalent security risk when an organization implements remote virtual private network (VPN) access to its network?

- A. Malicious code could be spread across the network
- B. VPN logon could be spoofed
- C. Traffic could be sniffed and decrypted
- D. VPN gateway could be compromised

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

VPN is a mature technology; VPN devices are hard to break. However, when remote access is enabled, malicious code in a remote client could spread to the organization's network. Though choices B, C and D are security risks, VPN technology largely mitigates these risks.

QUESTION 741

The use of digital signatures:

- A. requires the use of a one-time password generator.
- B. provides encryption to a message.
- C. validates the source of a message.
- D. ensures message confidentiality.

Correct Answer: C

Explanation

Explanation/Reference:

Section: Protection of Information Assets

The use of a digital signature verifies the identity of the sender, but does not encrypt the whole message, and hence is not enough to ensure confidentiality. A one-time password generator is an option, but is not a requirement for using digital signatures.

QUESTION 742

The FIRST step in a successful attack to a system would be:

- A. gathering information.
- B. gaining access.
- C. denying services.
- D. evading detection.

Correct Answer: A

Explanation

Explanation/Reference:

Section: Protection of Information Assets

Successful attacks start by gathering information about the target system. This is done in advance so that the attacker gets to know the target systems and their vulnerabilities. All of the other choices are based on the information gathered.